

STRICTLY INTERNAL

Księga 4.0 — operacyjny baseline techniczny

Ta warstwa jest przeznaczona dla zespołu wewnętrznego: architektów, platform engineering, SRE, SOC, bezpieczeństwa, backend/frontend, integratorów sprzętowych i osób prowadzących testy human regression.

Klasyfikacja	Wewnętrzne / restricted distribution / bez sekretów produkcyjnych.
Zakres wykonawczy	Runbooki legalnych modułów: portal, admin, operator, providerzy, G1/G2, Puli AX, Pixel, Firecracker, CDR, monitoring, testy.
Zakres wyłączony	Brak instrukcji manipulacji publicznymi identyfikatorami telekomunikacyjnymi, obchodzenia lawful controls albo ukrywania działań przed operatorami/regulatorami.

INT-1. Executive Technical Baseline

Wersja internal rozszerza Księgę 4.0 o procedury techniczne i kryteria wykonawcze dla zespołów wdrożeniowych. Jej celem jest usunięcie niejednoznaczności: każdy moduł ma mieć właściciela, wejścia, wyjścia, testy, logi, rollback i warunki produkcyjności.

Moduł	Owner	Wejście	Wyjście	Release gate
Portal	Web/Billing	tier, płatność, token	claim i bootstrap event	webhook signature + idempotency + token hash
Admin	Backend/Security	operator/provider/tier policy	provisioning plan	RBAC + step-up + audit
Operator	Frontend/Platform	sesja i subskrypcja	kontrola środowisk	quota + ownership + no cross-tenant data
G1	SRE	router/terminal cert	tunel do G2	VPN evidence + no bypass
G2	Platform	sesja operatora	stream workloadu	session cap + no content logging
Workload	Platform	app manifest	microVM/container	recreate proof + isolation proof
CDR	Security	file ingress/egress	allow/deny/quarantine	sanitization evidence
Monitoring	SOC	metadata	alert/incident	no content capture + incident SLA

INT-2. Portal Runbook

INT-2.1 Zakres portalu

Portal publiczny obsługuje zakup tokenu, claim tokenu, generację paczek startowych i inicjalizację operatora. Portal nie obsługuje panelu admina, panelu operatora ani streamingu workloadów.

INT-2.2 Procedura wdrożenia portalu

Krok	Działanie	Dowód	Rollback
1	Utworzyć osobny VPS portalowy i skonfigurować tylko publiczne route'y portalu.	inventory + firewall snapshot	remove DNS + destroy VPS
2	Skonfigurować TLS, HSTS, CSP i oddzielny secret do komunikacji z Admin API.	security header report	revoke edge secret
3	Podłączyć Stripe, CoinGate i Mollie w trybie testowym.	signed webhook test	disable payment provider
4	Włączyć token service: hash tokenu, typ tokenu, scope, termin ważności.	token ledger event	revoke unclaimed tokens
5	Uruchomić claim flow i sprawdzić atomowość jednorazowego użycia.	double-claim negative test	block claim route

INT-2.3 Testy portalu

- Zakup Pilot, Standard, Pro, Phantom i Sovereign w trybie sandbox.
- Webhook z poprawnym podpisem przechodzi, webhook bez podpisu jest odrzucony.
- Ten sam webhook nie tworzy dwóch tokenów.
- Token po claimie nie może być użyty drugi raz.
- Portal nie ma dostępu do route'ów admina/operatora/workload stream.

INT-3. Admin Panel Runbook

INT-3.1 Zakładki wymagane

Zakładka	Minimalne funkcje	Test
Dashboard	stan systemu, operatorzy, koszty, alerty, gates	Playwright + API status
Operators	lista operatorów, tier, koszt, G1/G2/workload, sesja, status	create/list/update
Providers	kraje, capabilities, koszty, KVM, Firecracker, TDX, SEV-SNP	provider capability matrix
Subscriptions	ceny, terminy, limity, upgrade, tokeny	quota enforcement
Apps	globalnie autoryzowane aplikacje i wersje desktop/web/native	operator cannot add global app
Monitoring	metadane ścieżki, anomalia, alerty, incydenty	synthetic anomaly
CDR	polityki plików, quarantine, decyzje	file flow tests
PHANTOM	hardening gates, lab-only records, human gates	execution stays false

INT-3.2 Zasady administracyjne

- Operacje provider secrets wymagają step-up.
- Operacje destrukcyjne wymagają four-eyes albo równoważnego gate'u.
- Panel admina nie pokazuje haseł, tokenów providerów, seedów, treści wiadomości ani danych walletów.
- Koszt operatora musi być liczony z G1, G2, workload, storage, transfer, dodatków i kosztu bare metal pool.

INT-4. Operator Panel Runbook

INT-4.1 Zakładki operatora

Zakładka	Funkcja	Dowód działania
Overview	status sesji, licznik, terminal, G1/G2/workload	session JSON + UI screenshot
Apps	launcher do aplikacji i panelu	Pixel ADB click-through
Workload Control	counts, recreate, prepare new session	microVM/container ID changes
Streaming	fit mode, keyboard, input tools	typing and scroll test
Security Unlock	hasła G1/G2/workload, session TTL, FIDO2 placeholder	expiry/re-auth test
Backup & Panic	backup, inactivity wipe, panic levels	dry-run + gated destructive test
Jurisdiction	kraje i częstotliwość w ramach tieru	policy deny/allow
Matrix Server	wniosek o własny serwer Matrix	provisioning plan

INT-4.2 Test human usability

Operator panel nie jest gotowy, jeśli da się go tylko otworzyć. Musi dać się przejść na Pixelu i laptopie: klik, scroll, wpisywanie, przełączenie aplikacji, powrót do panelu, reset aplikacji, ponowny start aplikacji.

INT-5. G1/G2 Runbook

INT-5.1 G1

- G1 jest indywidualne dla operatora.
- G1 przyjmuje tylko ruch z dopuszczonego terminal/router policy.
- G1 nie przechowuje danych aplikacyjnych.
- G1 ma mieć dowód tunelu do G2 oraz negatywny test braku bypassu.

INT-5.2 G2

- G2 brokuje sesję i dostęp do workloadu.
- G2 ma limit połączeń per operator i per user.
- G2 nie zapisuje treści streamu ani wejścia.
- Docelowy PHANTOM wymaga blind broker/E2EE stream.

INT-5.3 Dowody

Kontrola	Dowód	Wynik wymagany
G1 reachable only via allowed path	negative route tests	direct access denied
G1 to G2 tunnel	metadata + service health	healthy
G2 session cap	parallel connection test	over-limit denied
No stream persistence	storage/log grep	no content artifacts

INT-6. Workload i Firecracker Runbook

INT-6.1 Minimalny lifecycle środowiska

Stan	Opis	Akcja
planned	środowisko zaplanowane przez entitlement	operator może zobaczyć quota
prepared	obraz i manifest gotowe	można uruchomić
running	microVM/kontener działa	stream available
usable	aplikacja przeszła test człowieka	status app works
needs-account	aplikacja działa, ale wymaga konta/SMS	czeka na operatora
broken	aplikacja nie działa lub stream/input zepsuty	defect + recreate
destroyed	środowisko usunięte	audit + cleanup proof

INT-6.2 Aplikacje wymagane

Każda aplikacja ma mieć status per wersja: desktop, web, Android-native. Jeżeli web nie pozwala założyć konta, status nie może być "works"; powinien być "limited" albo "needs native".

Aplikacja	Tryby	Test minimum
DuckDuckGo	desktop/web	search, typing, scroll, cookies, page load
LibreOffice	desktop	open, edit, save test doc, recreate
Signal	desktop/native	start, account state, QR/SMS handoff
Telegram	desktop/web/native	start, phone/SMS handoff, session state
WhatsApp	desktop/web/native	start, QR/phone handoff, limitations explicit
Threema	desktop/web/native	start, license/account state
Zangi	native/desktop where available	APK provenance, auth state, stream
Exodus	desktop	launch only, no seed/private key capture

INT-7. Pixel, Puli AX i terminal admission

INT-7.1 Pixel

- Pixel ma mieć profil GrapheneOS, certyfikat CA, browser profile i shortcut do panelu operatora.
- Nie wolno zapisywać danych aplikacyjnych na terminalu.
- Test ADB musi potwierdzić klik, scroll, keyboard, app switching i powrót do panelu.

INT-7.2 Puli AX

- Puli AX ma mieć paczkę routera, tunel do G1, kill switch i DNS leak prevention.
- Router ma raportować status do panelu, ale nie być jedynym zaufanym końcem bezpieczeństwa.
- Po restarcie routera Pixel powinien odzyskać ścieżkę bez ręcznego obchodzenia policy.

INT-7.3 PHANTOM admission

W PHANTOM dostęp do G1 wymaga korelacji terminala, routera i FIDO2. Jeśli jeden element nie przechodzi policy, system ma zablokować sesję.

INT-8. Monitoring, CDR i incident response

INT-8.1 Blue-team metadata

Monitoring ma widzieć ścieżkę i anomalie, ale nie treść pracy operatora. Zbieramy metadane, statusy, błędy, czasy, identyfikatory środowisk, decyzje CDR i alerty.

INT-8.2 Incident response

Sygnal	Reakcja	Gate
zmiana klucza bez planu	freeze operator session, revoke suspect cert	SOC + Security
próba direct bypass G1/G2	block source, create incident, rotate credentials	SRE
CDR quarantine spike	raise risk level, notify admin, hold files	Security
workload escape signal	stop host, isolate workload, preserve metadata evidence	Critical gate
panic code	execute configured legal policy level	pre-approved policy

INT-9. PHANTOM Internal Annex Boundary

PHANTOM może mieć wewnętrzne aneksy prawne i laboratoryjne poza repo. W Księdze 4.0 widoczna jest struktura, wymagania, testy, ryzyka i human gates. Instrukcje wykonawcze dotyczące obszarów regulowanych muszą być prowadzone przez uprawniony zespół prawny/telekom/lab i przechowywane w odrębnym kontrolowanym repozytorium albo sejfie dokumentów.

Obszar	Status w Księdze	Gdzie może istnieć szczegółowy SOP
RF lab	governance i test preflight	zewnętrzny lab SOP po legal approval
SIM/modem identity	risk model i compliance boundary	autoryzowane środowisko laboratoryjne
Traffic camouflage	legal review i threat model	counsel-approved research annex
Forensic response	incident response i retention policy	legal IR playbook

SPIS TREŚCI TECHNICZNY

Spis treści jest statyczną mapą wewnętrzną Księgi 4.0. Wersja PDF generowana przez Chromium nie ma automatycznych numerów stron w treści, dlatego ten spis pełni rolę mapy sekcji, a nie indeksu stron.

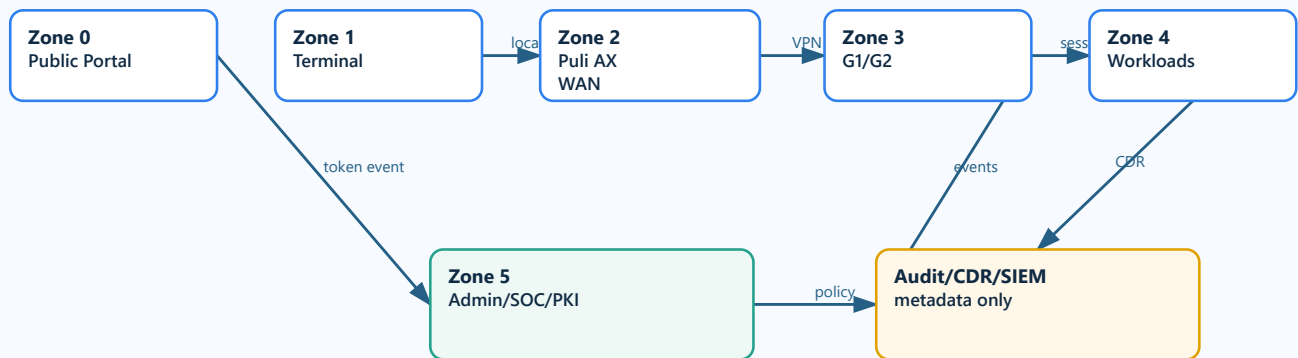
Sekcja	Nazwa	Zakres
0	Strictly Internal cover	Klasyfikacja, zakres, ograniczenia i bezpieczne granice dokumentu.
INT-1	Executive Technical Baseline	Mapa modułów, ownerów, wejść, wyjść i release gates.
INT-2	Portal Runbook	Pierwszy, skrócony runbook portalu i testów płatności/tokenów.
INT-3	Admin Panel Runbook	Zakładki, zasady, RBAC, providerzy, koszty, subskrypcje, CDR i monitoring.
INT-4	Operator Panel Runbook	Środowiska aplikacji, streaming, sesje, backup, panic, rotacja i Matrix.
INT-5	G1/G2 Runbook	Gateway, broker, brak bypassu, dowody tuneli i session caps.
INT-6	Workload i Firecracker	Lifecycle środowisk, aplikacje, tryby desktop/native, recreate proof.
INT-7	Pixel, Puli AX i terminal admission	Terminal, router, certyfikaty, pakiety i PHANTOM admission.
INT-8	Monitoring, CDR i incident response	Metadane, alerty, CDR, playbooki i granice widoczności.
INT-9	PHANTOM Internal Annex Boundary	Rozdział baseline, governance, lab-only i restricted SOP.
A	Security & Architecture Atlas	Diagramy, STRIDE, wektory zagrożeń, kontrola izolacji i brokerów.
B	Księga SYLION v3.4 FIXED import	Pełny import źródłowej Księgi 3.4 dla traceability.
C	PHANTOM v3.0 source index	Indeks struktury PHANTOM i rozdzielenie warstw [A]/governance.
X	Portal zakupowy, płatności, tokeny i resellerzy	B2C, B2B, crypto, Stripe, CoinGate, Mollie, token lifecycle, UI i privacy.
Z	Końcowe porównanie i panel administratora	3.4 vs PHANTOM vs 4.0, admin console, blue-team observation, KPI/SLO.
Y	Scenariusze ataków i obrona per tier	Attack paths, Pilot/Standard/Pro/Phantom/Sovereign, residual risks i testy.
W	Rozszerzony masterplan modułów i testów	Szczegółowe opisy modułów, workflow, dane, kontrole, awarie i kryteria odbioru.

SECURITY & ARCHITECTURE ATLAS — grafy, macierze, porównania

Ten atlas jest warstwą wizualną Księgi 4.0. Pokazuje granice zaufania, wektory zagrożeń, przepływy obronne, porównania technologiczne i dowody wymagane do uznania funkcji za działającą. Diagramy są defensywne i audytowe; nie są instrukcjami obchodzenia zewnętrznych systemów kontroli.

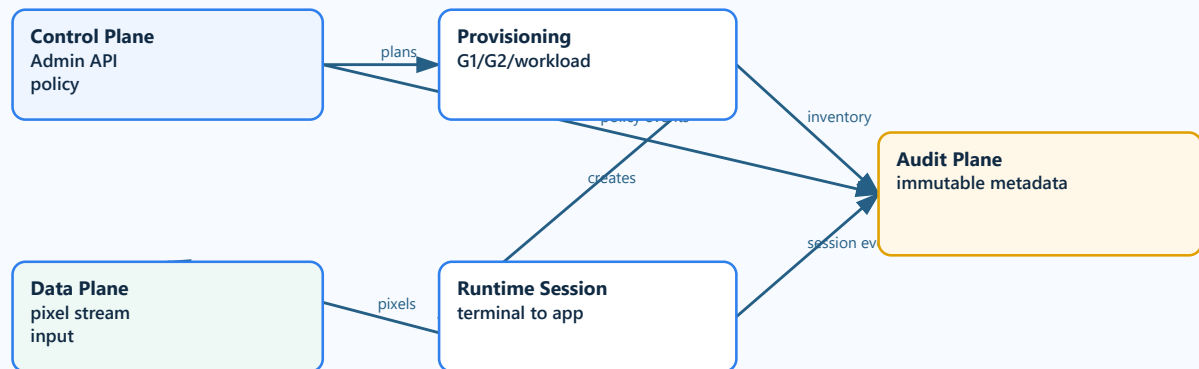
A1. Zone model 0-5 i granice zaufania

A1. Zone model 0-5 i granice zaufania



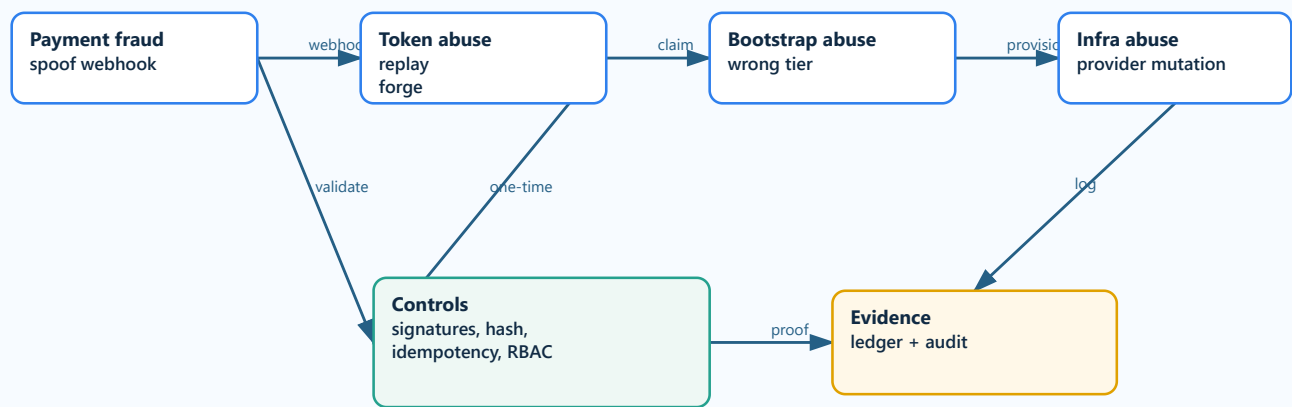
A2. Control plane, data plane i audit plane

A2. Control plane, data plane i audit plane



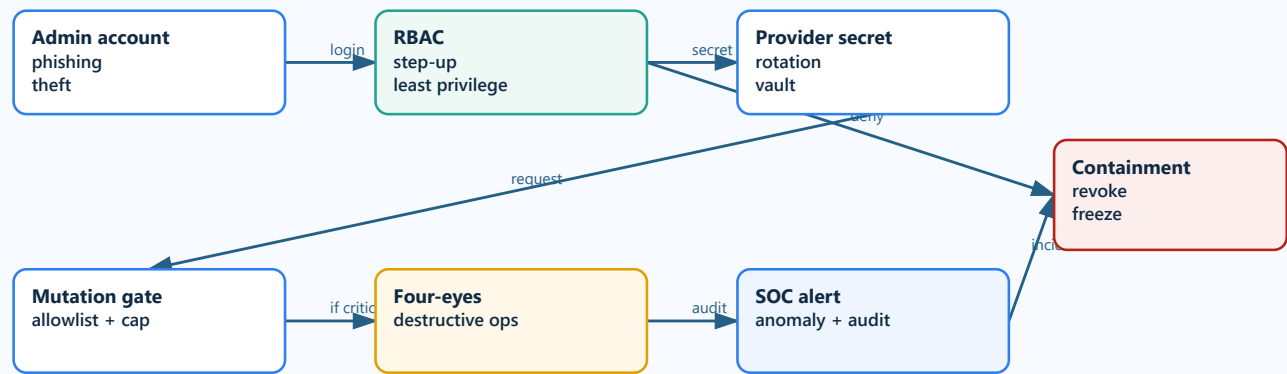
A3. Threat map portalu, tokenów i bootstrapu

A3. Threat map portalu, tokenów i bootstrapu

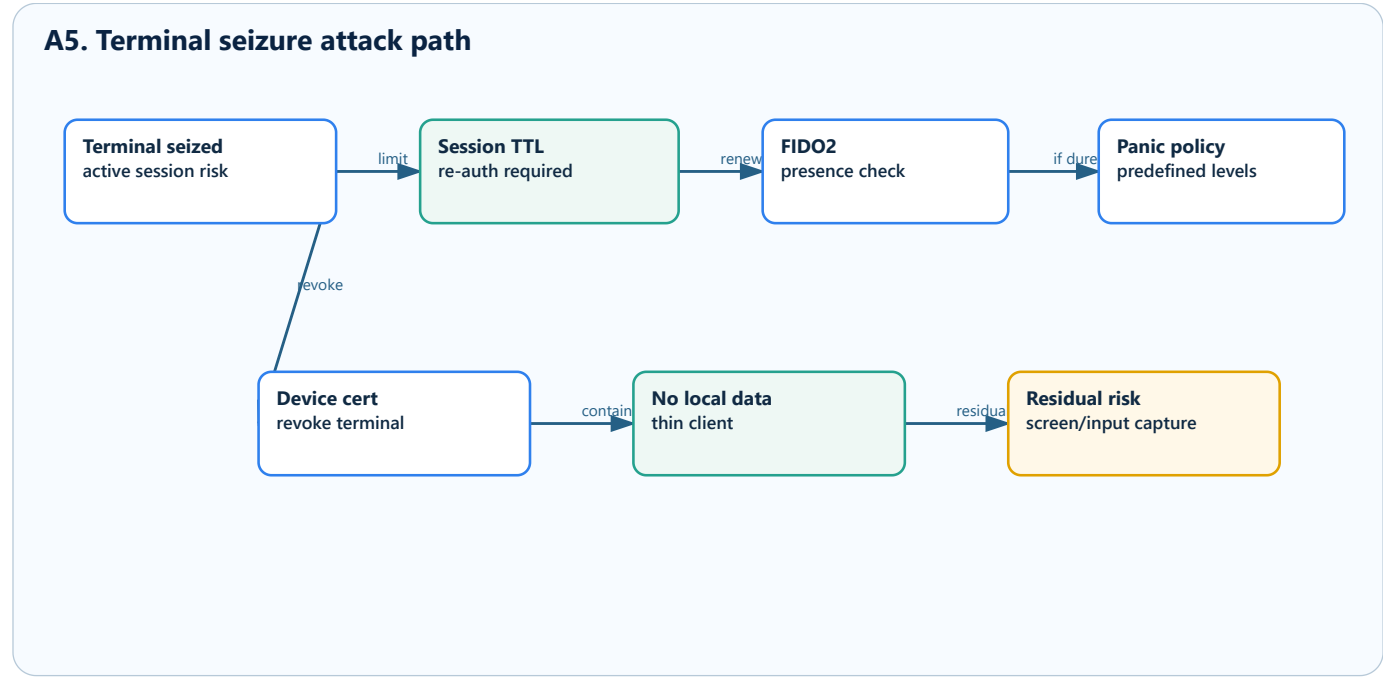


A4. Admin compromise containment flow

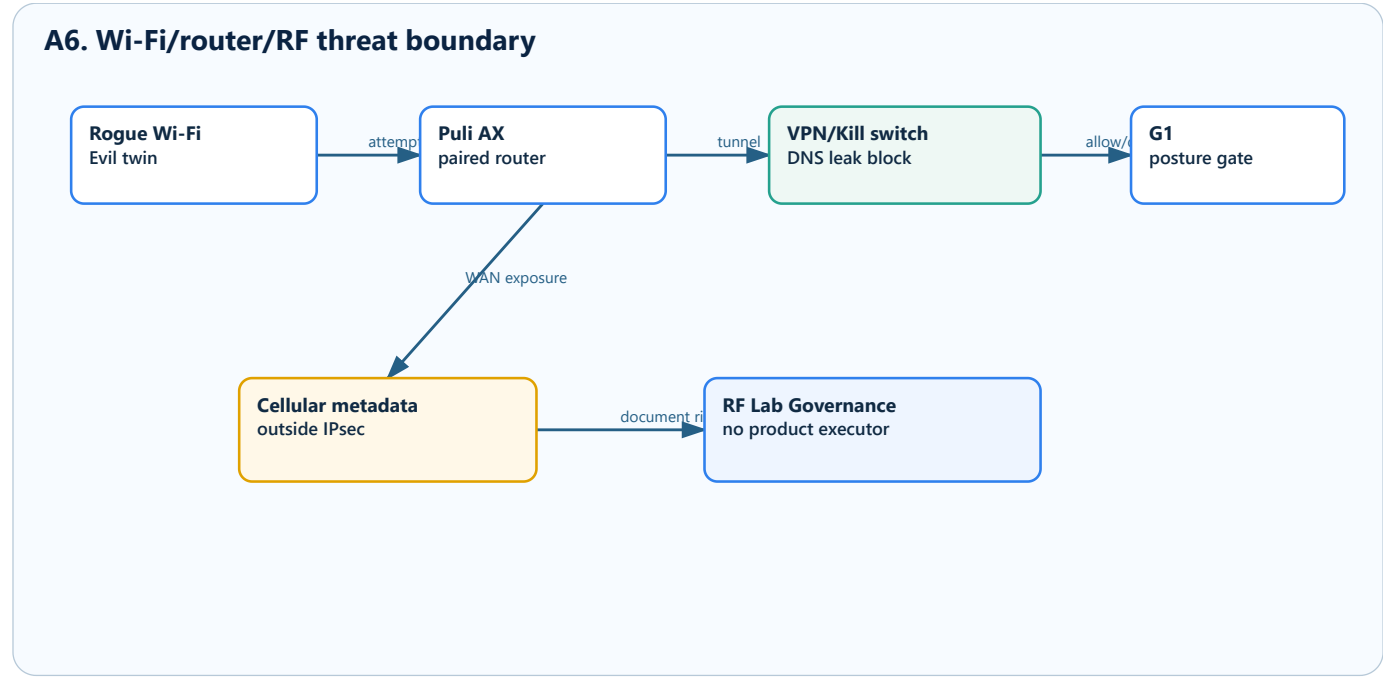
A4. Admin compromise containment flow



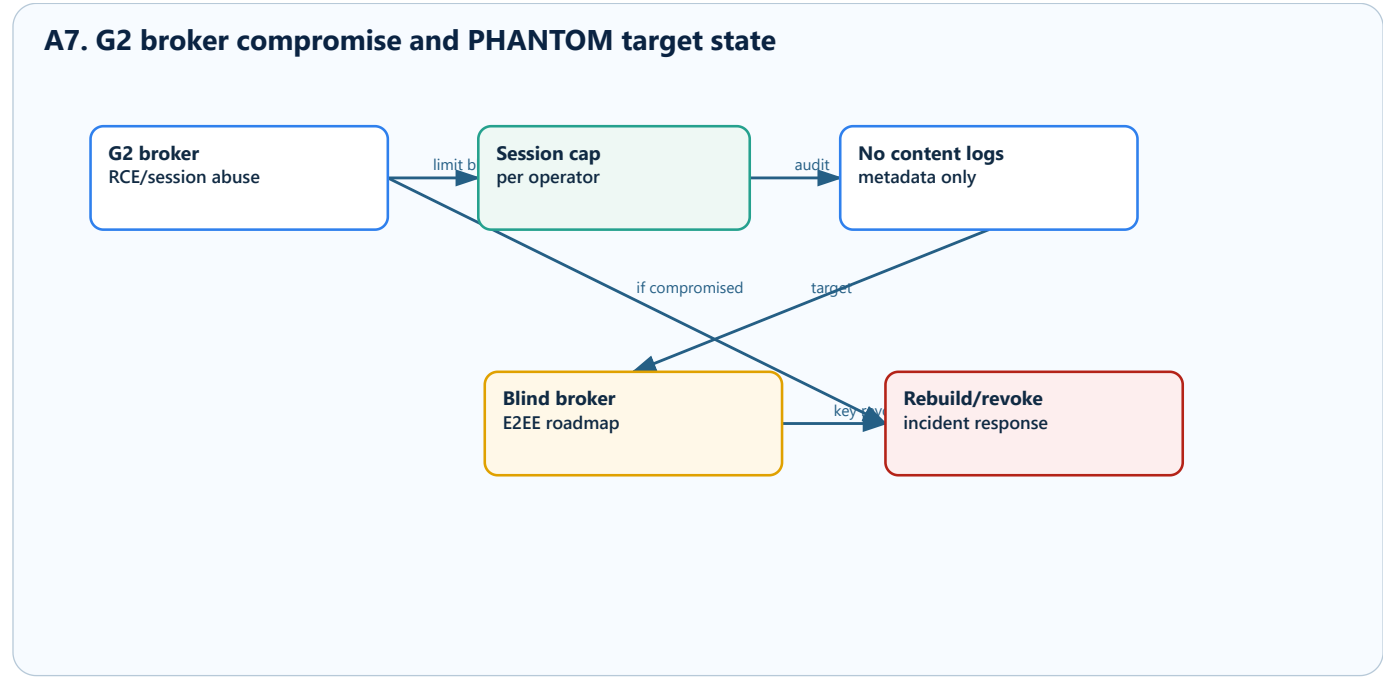
A5. Terminal seizure attack path



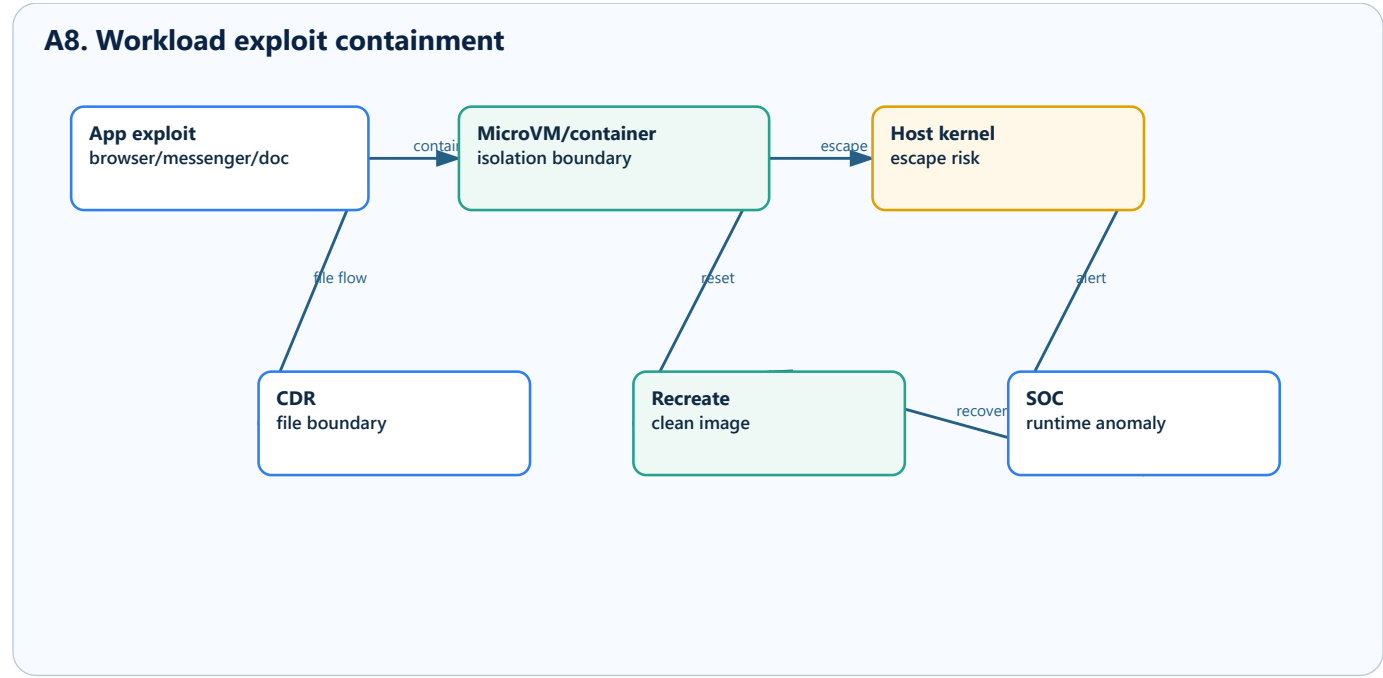
A6. Wi-Fi/router/RF threat boundary



A7. G2 broker compromise and PHANTOM target state

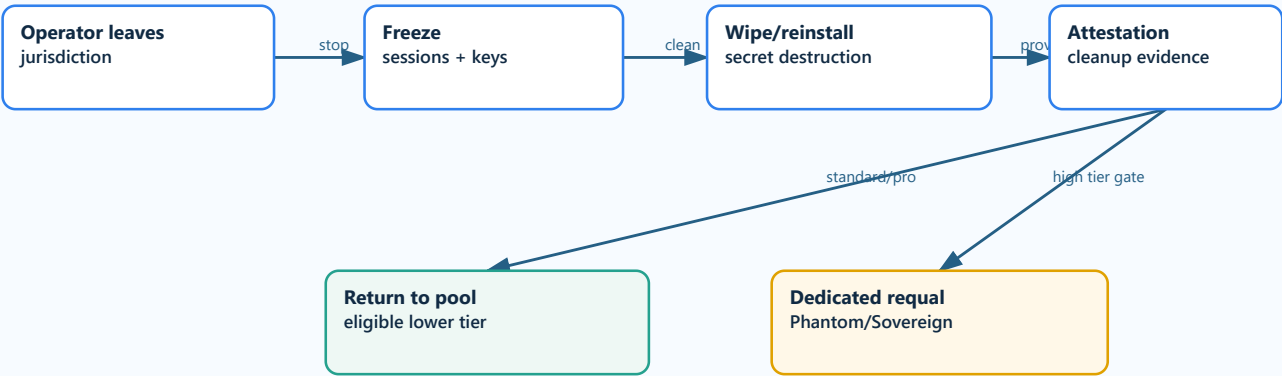


A8. Workload exploit containment



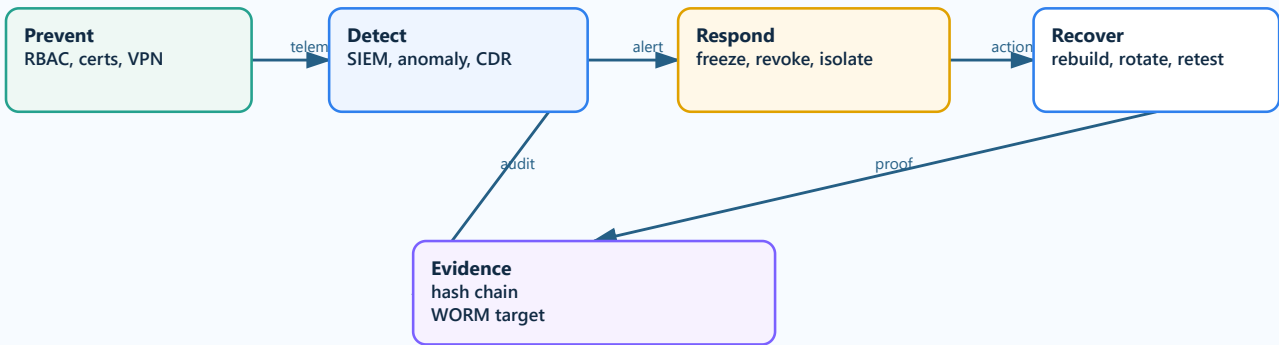
A9. VPS reuse safety lifecycle

A9. VPS reuse safety lifecycle



A10. Prevent - detect - respond - recover loop

A10. Prevent - detect - respond - recover loop



A11. Macierz głównych wektorów zagrożeń

Wektor	Powierzchnia	Cel atakującego	Kontrola	Dowód/test	Ryzyko
Portal webhook spoof	payment/portal	free token or wrong tier	signed webhook, idempotency, token ledger	double-spend and forged signature tests	Medium
Token replay/theft	portal/token	unauthorized bootstrap	hash token, one-time claim, expiry, scope	double claim negative test	Medium
Admin credential theft	admin	provider mutation, operator abuse	FIDO2/step-up, RBAC, four-eyes, audit	privilege boundary test	High
Provider secret leak	admin/secrets	infrastructure takeover	vault adapter, secret refs, no plaintext logs	secret grep and audit leakage test	High
Terminal seizure	Pixel/laptop	active session access	session TTL, FIDO2, revoke cert, no local data	ADB seizure simulation	High
Rogue Wi-Fi	Pixel/router	traffic interception	router pairing, VPN, kill switch, cert policy	evil twin negative test	Medium
Router compromise	Puli AX	traffic manipulation	terminal-to-G1 crypto, kill switch, router hardening	route/DNS leak tests	High
G1 compromise	G1	pivot to G2 or metadata	per-operator G1, no app data, revoke/rebuild	G1 isolation test	Medium
G2 compromise	G2	stream/session exposure	session cap, no persistence, blind broker roadmap	no content log test	High
App exploit	workload app	control app env	Firecracker/container, recreate, CDR	app exploit containment drill	High
VM/container escape	workload host	host takeover	kernel hardening, dedicated hosts, monitoring	escape simulation/lab only	Critical
File-borne malware	CDR	payload transfer	sanitize, quarantine, hash, allow/deny	malicious doc test corpus	High
Provider snapshot	VPS/bare metal provider	data/metadata capture	encryption, minimal state, dedicated tier, rotation	provider threat review	High
Insider abuse	admin/SRE/SOC	unauthorized action	RBAC, four-eyes, WORM audit, separation of duties	dual-control negative test	High

Metadata correlation	network/global observer	operator linkage	jurisdictional policy, traffic review, OPSEC	traffic metadata review	High
Backup exfiltration	backup	data theft	encrypted backup, operator ownership, CDR, access audit	restore and access test	Medium
Panic abuse	operator/admin	data loss/cover-up	predefined policy levels, audit, approval gates	dry-run panic tests	High
Matrix federation abuse	Matrix add-on	metadata leak or spam	federation policy, moderation, Tor/onion governance	Matrix threat test	Medium

A12. STRIDE per komponent

Komponent	Spoofing	Tampering	Repudiation	Information disclosure	DoS	Elevation
Portal	spoofed webhook	token tamper	payment denial	invoice data	not applicable	claim abuse
Admin panel	admin impersonation	provider policy tamper	audit dispute	secret leakage	service disable	privilege escalation
Operator panel	session hijack	quota tamper	operator action dispute	own metadata	session exhaustion	access to other operator
Pixel	device clone	cert tamper	local action dispute	screen/input	battery/network DoS	terminal privilege
Puli AX	router impersonation	route/DNS tamper	config dispute	WAN metadata	WAN loss	LAN pivot
G1	gateway spoof	VPN policy tamper	tunnel log dispute	metadata	gateway DoS	pivot to G2
G2	broker spoof	session tamper	stream action dispute	pixel stream	session cap exhaustion	broker RCE
Workload	app env spoof	image tamper	app action dispute	files/messages	resource exhaustion	VM escape
CDR	policy spoof	file transform tamper	decision dispute	file metadata	queue DoS	policy override
Provider	fake region	host tamper	SLA dispute	snapshots/metadata	provider outage	provider admin

A13. Kontrole, dowody i ryzyka rezydualne

Warstwa	Kontrola	Dowód	Ryzyko rezydualne
Terminal	no local data, certs, session TTL	ADB human regression, storage checks	active compromise exposes current view
Router	kill switch, DNS leak prevention, VPN to G1	route loss and DNS leak tests	baseband and firmware remain residual
G1	per-operator gateway, no app data	direct bypass negative tests	metadata and DoS
G2	session limits, no content persistence	storage/log tests	needs blind broker for PHANTOM
Workload	Firecracker, recreate, quotas	app usability and recreate proof	host escape risk
CDR	sanitize/quarantine/hash	malicious corpus tests	unknown file formats
Admin	RBAC, step-up, four-eyes	permission matrix tests	insider risk
Portal	signed webhooks, token hash	payment/token tests	phishing token theft
Provider	capability registry, region policy	provider qualification	provider metadata
PHANTOM	human gates, lab-only governance	evidence review	not all RF risks solvable in software

A14. Porównanie izolacji workloadów

Kryterium	Kontenery	Firecracker	Dedicated bare metal	Confidential computing
Isolation model	Containers	Firecracker	Dedicated bare metal	Confidential computing
Primary strength	density and cost	microVM isolation	physical/logical control	attested memory protection
Primary weakness	kernel shared	host kernel still shared	cost/provisioning time	provider/hardware support varies
Use in tiers	Pilot/Standard	Pro+	Phantom/Sovereign	Phantom/Sovereign when qualified
Evidence required	container isolation tests	microVM lifecycle tests	inventory/attestation	attestation quote validation

A15. Porównanie brokerów streamingu

Broker	Mobile UX	Security posture	PHANTOM fit	Known issue
Broker	Mobile UX	Security posture	PHANTOM fit	Known issue
Guacamole	good cross-protocol	broker-visible unless hardened/E2EE added	intermediate only	input bridge and clear broker risk
KasmVNC	good for browser VNC/mobile controls	TLS/session controls, broker still important	intermediate candidate	side menu/keyboard UX
noVNC	simple	depends on transport/session wrapper	lower	same keyboard/menu issues possible
Custom E2EE/SFrame	requires build	best target if keys stay outside broker	target	engineering complexity

A16. Hierarchia dowodów testowych

Poziom	Dowód	Co może potwierdzić
E0	written requirement	test intent only
E1	static review	contract and controls
E2	unit/contract tests	API invariants
E3	integration tests	multi-module behavior
E4	live metadata probes	path health and reachability
E5	human/ADB interaction	actual usability
E6	negative security tests	boundary enforcement
E7	repeatable regression	release confidence
E8	human gate	approval state, not new evidence

Księga 4.0

SYLION Secure + PHANTOM v3.0

Pełny baseline techniczny, architektura, modułowość, panele, tiering, rotacje, analiza zagrożeń, PHANTOM governance i aktualny stan wdrożenia.

Data	2026-06-01
Źródła	SYLION Księga v3.4 FIXED, PHANTOM v3.0, dokumenty admin-panel-v2, implementacja services/admin-api.
Status	Baseline 4.0 draft do dalszej redakcji i human gate. Nie jest claimem pełnej produkcyjności.
Granica bezpieczeństwa	Opis defensywnej architektury i governance. Brak sekretów, brak executorów RF/telecom, brak instrukcji obchodzenia zabezpieczeń.

Rozdział 0. Korekta względem poprzedniego artefaktu

Poprzedni PDF był krótkim skrótem. Księga 4.0 w tej wersji ma inną funkcję: jest dokumentem bazowym i śladem scalającym pełną Księgę 3.4, profil PHANTOM v3.0 i aktualny stan implementacji. Z tego powodu zawiera pełny import materiału źródłowego Księgi 3.4, osobną warstwę aktualizacji 4.0, diagramy oraz profil PHANTOM przepisany do formy bezpiecznej architektonicznie.

Najważniejsza zasada interpretacyjna: jeżeli tekst odziedziczony z Księgi 3.4 albo PHANTOM v3.0 jest sprzeczny z warstwą aktualizacji 4.0, nadrzędna jest warstwa 4.0. Szczególnie dotyczy to routera Puli AX, granic PHANTOM, portalu zakupowego, tokenów, nowego tieringu i polityki reuse VPS.

Rozdział 1. Normatywny baseline Księgi 4.0

Obszar	Wymaganie	Status
Terminal	Terminal jest cienkim klientem i nie przechowuje danych roboczych operatora.	Baseline
G1/G2	Każdy operator ma indywidualne G1 i G2. Współdzielenie tych warstw wymaga ADR i human gate.	Baseline
Workload	Workloady są izolowane per operator i aplikacja zgodnie z tierem. Pro i wyżej wymagają Firecracker albo silniejszej izolacji.	Baseline/PHANTOM
CDR	CDR jest obowiązkowe dla plików i przepływów między strefami.	Baseline
Portal	Portal publiczny działa na osobnym VPS i komunikuje się z prywatnym Admin API wyłącznie przez allowlistowane endpointy.	Baseline
Providerzy	Administrator zarządza provider registry: kraje, koszty, KVM, Firecracker, TDX, SEV-SNP, bare metal.	Baseline
Rotacja	Rotacja jest funkcją subskrypcji i policy engine, nie dowolnym przyciskiem operatora.	Baseline
PHANTOM	PHANTOM jest profilem rozszerzonym, nie może automatycznie odblokowywać baseline execution.	PHANTOM
RF/telecom	Elementy RF, SIM, modem i identyfikatory są lab-only governance, bez executorów produktu.	Lab-only

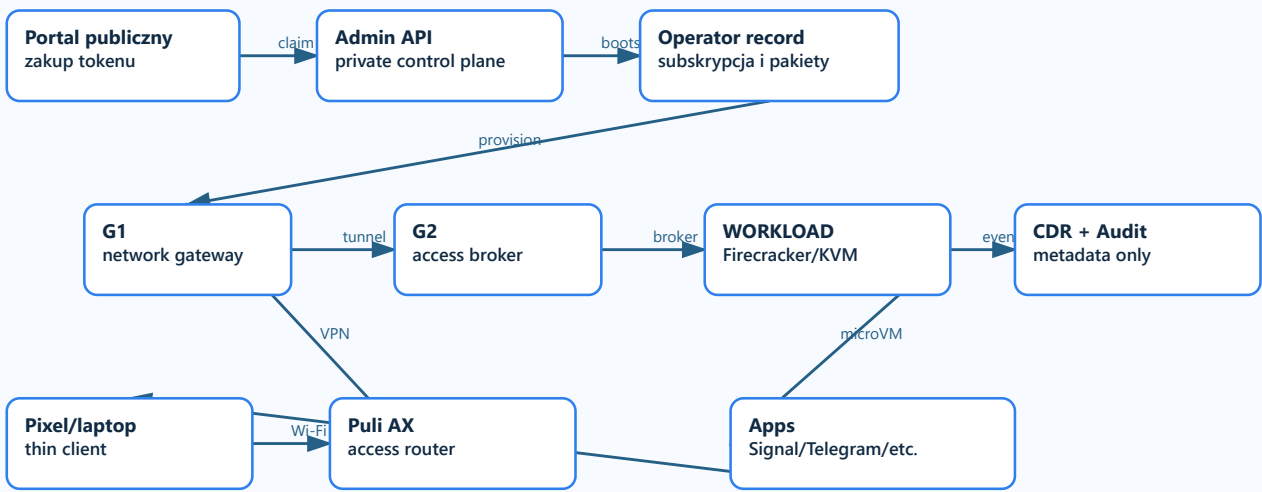
Rozdział 2. Nowe elementy 4.0 względem Księgi 3.4

- Puli AX jest aktualnym routerem roboczym dla ścieżki mobilnej. Starsze odniesienia do innych routerów są legacy albo wymagają ponownej kwalifikacji.
- Portal zakupowy jest oddzielną strefą publiczną, z tokenami, płatnościami Stripe/CoinGate/Mollie i scenariuszem resellerów.
- Minimalny publiczny okres subskrypcji wynosi 12 miesięcy. Starsze 6-miesięczne guardy administracyjne wymagają harmonizacji.
- Każdy operator ma indywidualne G1 i G2. Workload bare metal może być współdzielony tylko w niższych tierach i tylko po izolacji oraz sanitizacji.
- PHANTOM i Sovereign wymagają dedykowanych albo operator-only workloadów.
- Reuse VPS po innym operatorze jest dopuszczalne tylko po wipe, reinstall, zniszczeniu sekretów, rekwalifikacji i dowodzie audytowym.
- Panel operatora musi umożliwiać kontrolę własnych środowisk: reset, recreate, aplikacje, session TTL, backup, panic, Matrix, rotacje i monitoring własnej ścieżki.
- Panel administratora musi być konsolą blue-team: operatorzy, providerzy, koszty, alerty, anomalie, CDR, rotacje, status G1/G2/workload.
- Testy muszą być factual: aplikacja działa dopiero wtedy, gdy człowiek/ADB potwierdzi używalność, a nie tylko HTTP 200 albo działający proces.

Rozdział D. Diagramy i grafy Księgi 4.0

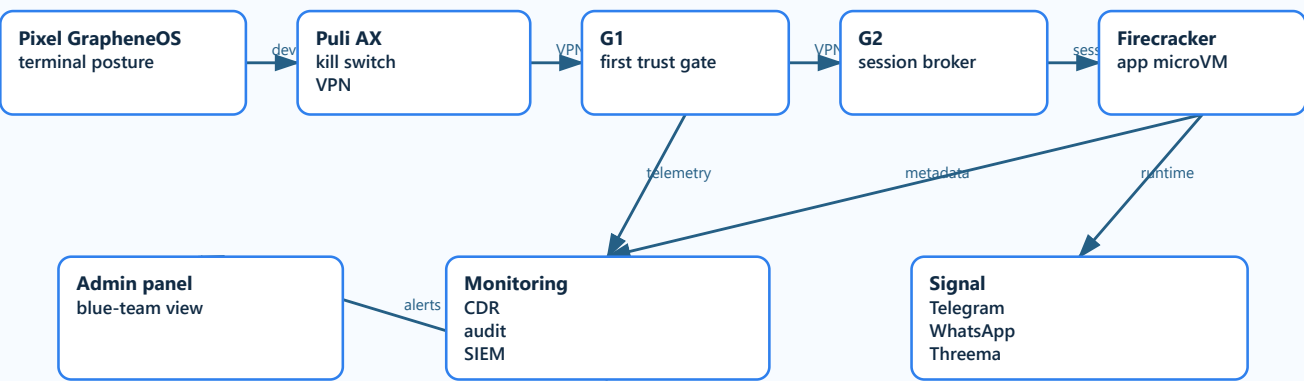
D1. Architektura logiczna SYLION 4.0

D1. Architektura logiczna SYLION 4.0



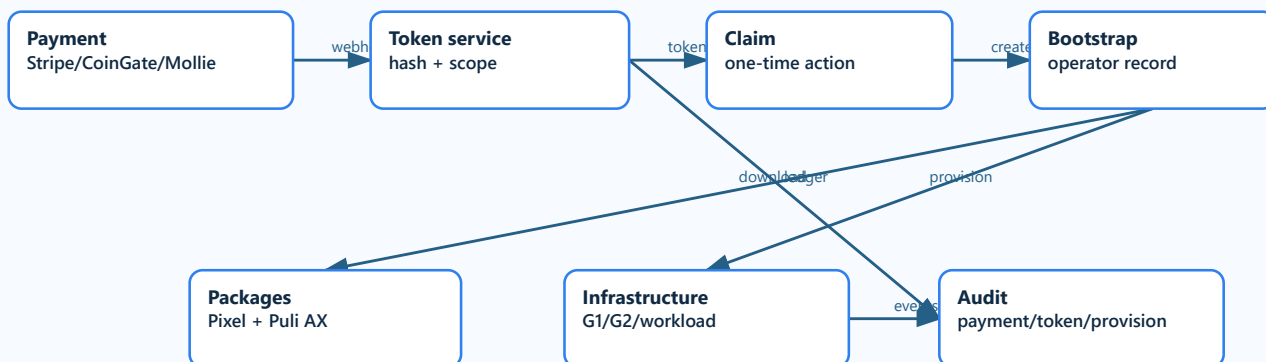
D2. Ścieżka Pixel - Puli AX - G1 - G2 - workload

D2. Ścieżka Pixel - Puli AX - G1 - G2 - workload



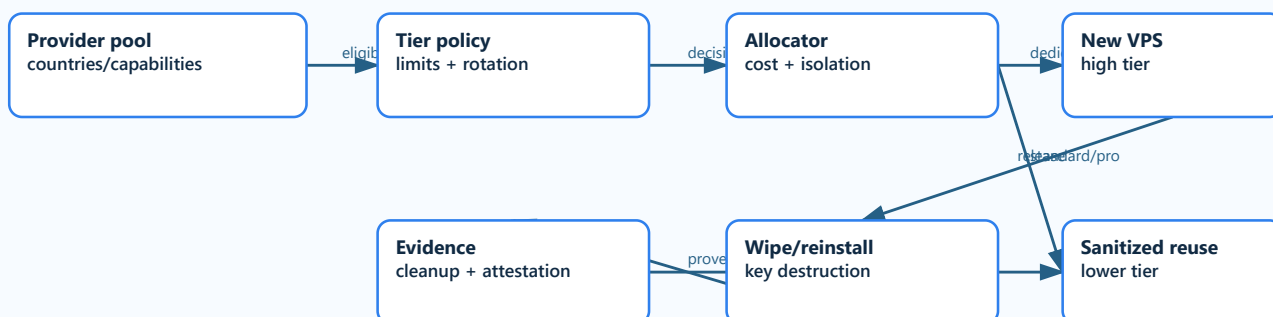
D3. Portal, płatność, token i bootstrap operatora

D3. Portal, płatność, token i bootstrap operatora



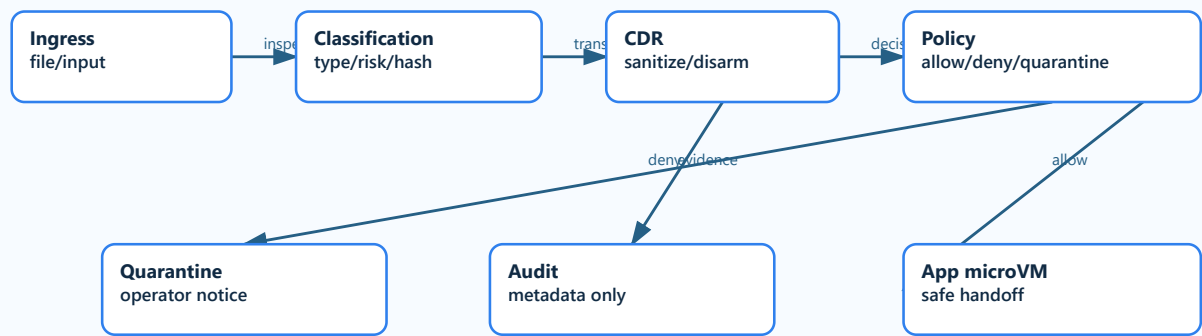
D4. Rotacja jurysdykcyjna i reuse VPS po operatorze

D4. Rotacja jurysdykcyjna i reuse VPS po operatorze



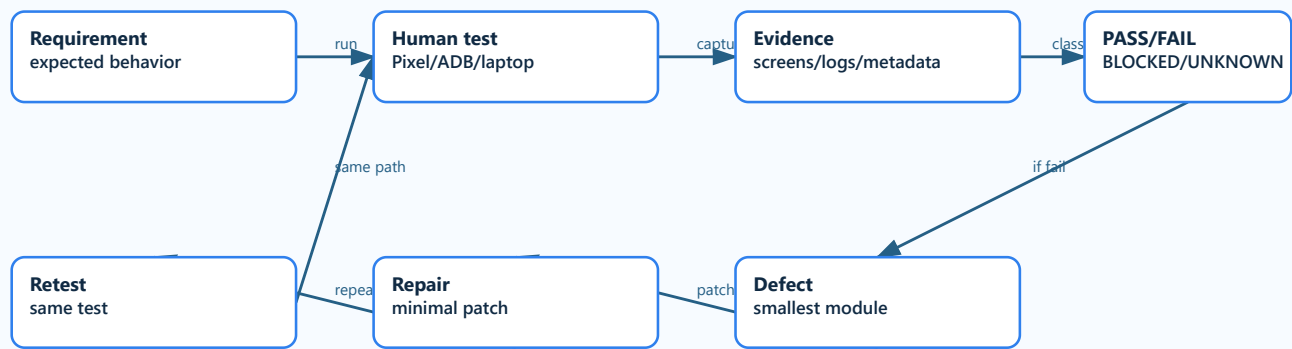
D5. CDR i kontrola przepływu plików

D5. CDR i kontrola przepływu plików



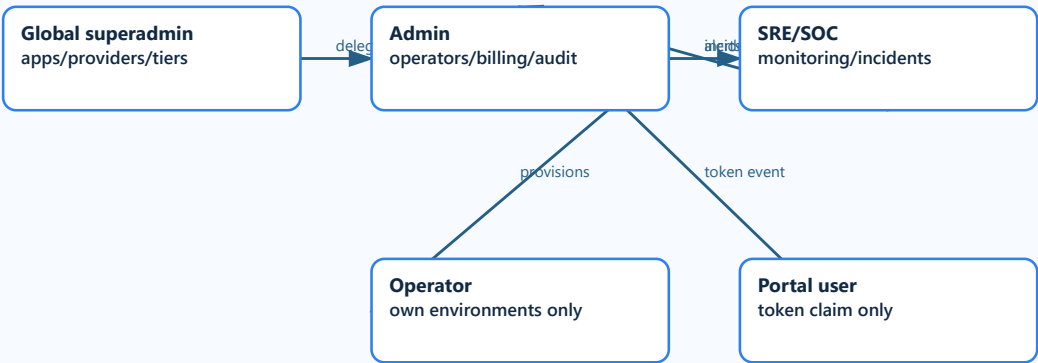
D6. Antyhalucynacyjny cykl test - naprawa - retest

D6. Antyhalucynacyjny cykl test - naprawa - retest



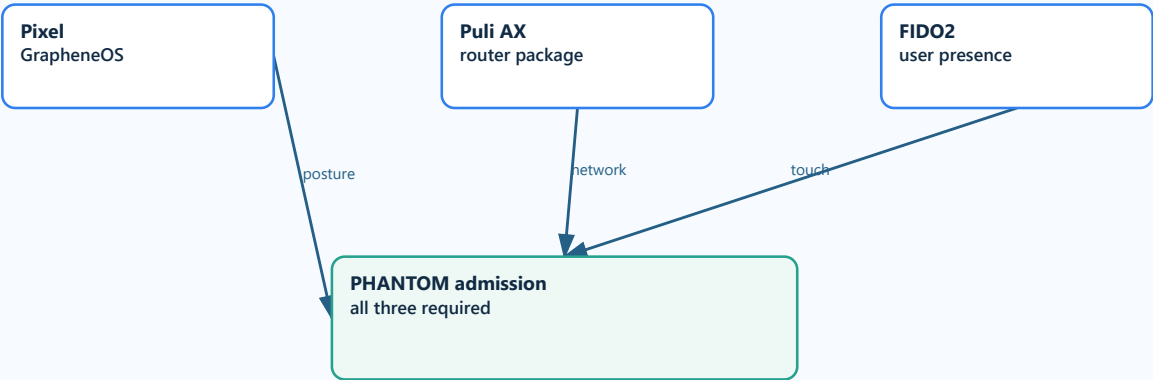
D7. Role i uprawnienia paneli

D7. Role i uprawnienia paneli



D8. PHANTOM: trójca sprzętowa

D8. PHANTOM: trójca sprzętowa



Rozdział 3. Tiering, ceny i limity 4.0

Tier	Cena/mies.	Cena roczna	Środowiska	Workload	Rotacja
Pilot	99 EUR	1 188 EUR	6	shared pool / kontenery	brak domyślnie
Standard	199 EUR	2 388 EUR	10	shared pool / kontenery	manualna ograniczona
Pro	499 EUR	5 988 EUR	20	Firecracker pool	harmonogram i provider rotation
Phantom	1 000 EUR	12 000 EUR	40	dedykowany / operator-only	pełna polityka
Sovereign	2 999 EUR	35 988 EUR	60	operator-only dedicated	pełna polityka + najwyższa izolacja

CDR jest obowiązkowe we wszystkich tierach. G1 i G2 są indywidualne dla każdego operatora. Różnica między tierami dotyczy przede wszystkim liczby środowisk, rodzaju izolacji workloadów, prawa do rotacji, dostępu do Matrix, dedykacji hostów oraz wymagań PHANTOM.

Rozdział 4. Funkcjonalności panelu administratora

Zakładka / obszar	Funkcjonalność
Operatorzy	tworzenie, status, tier, koszt, G1/G2/workload, pakiety, audit
Providerzy	kraje, regiony, KVM, Firecracker, TDX, SEV-SNP, bare metal, ceny
Subskrypcje	ceny, terminy, limity, upgrade, tokeny, resellerzy
Monitoring	alerty, anomalie, zmiany kluczy, błędy CDR, status tuneli
PHANTOM	hardening gates, lab-only records, human gate, brak automatycznego execution
CDR	polityki plików, quarantine, hash, decyzje allow/deny

Panel administratora jest prywatną konsolą sterowania i blue-team. Nie powinien być wystawiony publicznie. Musi pokazywać koszt utrzymania każdego operatora, jego tier, aktualny status G1/G2/workload, rotacje, alerty i problemy produkcyjne.

Rozdział 5. Funkcjonalności panelu operatora

Zakładka / obszar	Funkcjonalność
Sesja	licznik czasu, odblokowanie, hasła G1/G2/workload, FIDO2 później
Aplikacje	Signal, Telegram, WhatsApp, Threema, Zangi, DuckDuckGo, LibreOffice, Exodus
Środowiska	liczba instancji według tieru, reset, recreate, prepare new session
Rotacje	kraje, providerzy, częstotliwość i polityki tylko w granicach tieru
Backup/Panic	backup operatora, auto-wipe po nieaktywności, panic code z poziomami skutku
Matrix	wniosek o własny serwer Matrix jako opcjonalny add-on

Operator nie zarządza globalną platformą. Zarządza własnym środowiskiem: sesją, aplikacjami, resetem microVM/kontenerów, backupiem, panic, Matrix i rotacją dostępną w jego tierze.

Rozdział 6. Polityka reuse VPS i rotacji po operatorze

Niższe tiery mogą być przenoszone na oczyszczone zasoby po innych operatorach. Warunkiem jest pełny cleanup: zakończenie sesji, odpięcie operatora, zniszczenie sekretów, wipe danych, reinstall albo rebuild, nowe certyfikaty, nowe klucze, nowy binding, dowód audytowy i brak otwartych alertów.

Wysokie tiery, zwłaszcza Phantom i Sovereign, wymagają dedykacji albo formalnej rekwalifikacji zasobu. To oznacza, że zasób po innym operatorze może zostać użyty tylko po uznaniu go za czysty, pusty i zgodny z profilem dedykowanym.

Tier	Reuse G1/G2	Reuse workload	Warunek
Pilot	nie dla aktywnych operatorów	tak, z puli	wipe + nowe sekrety + audit
Standard	nie dla aktywnych operatorów	tak, z puli	wipe + reinstall + audit
Pro	nie dla aktywnych operatorów	tak, Firecracker pool	cleanup gates + capacity + provider policy
Phantom	tylko po pełnej rekwalifikacji	dedykowany/operator-only	human gate + attestation + compliance approval
Sovereign	zasadniczo brak współdzielenia	operator-only	formalna rekwalifikacja albo nowy host

CZĘŚĆ B — Import pełnej Księgi SYLION v3.4 FIXED jako baseline traceability

Kwiecień 2026

Spis treści

KLASYFIKACJA: POUFNE / CONFIDENTIAL Wersja dokumentu: 3.0.0-draft Data: 2026-04-05 Właściciel: SYLION AG (Szwajcaria)

Ten dokument stanowi normatywną podstawę architektury, bezpieczeństwa, operacji i zgodności systemu SYLION 3.0. Zawiera 131 rozdziałów pogrupowanych w 17 części. Każdy rozdział oznaczony jest statusem normatywności, odbiorcą docelowym, wpływem na baseline oraz powiązaniem z innymi rozdziałami.

Spis treści:

Część I (roz. 1–7): Fundament dokumentu

Część II (roz. 8–16): Wizja, strategia, model biznesowy

Część III (roz. 17–23): Wymagania i przypadki użycia

Część IV (roz. 24–31): Architektura kontekstowa

Część V (roz. 32–51): Moduły systemowe

Część VI (roz. 52–61): API, kontrakty i dane

Część VII (roz. 62–71): Bezpieczeństwo i obrona

Część VIII (roz. 72–78): PQC i kryptografia

Część IX (roz. 79–84): Operacje i CI/CD

Część X (roz. 85–90): Monitoring i obserwowalność

Część XI (roz. 91–97): Testy, SRE, resilience

Część XII (roz. 98–104): Zarządzanie incydentami i forensics

Część XIII (roz. 105–108): Dokumentacja i wiedza

Część XIV (roz. 109–113): Infrastruktura i deployment

Część XV (roz. 114–119): Zgodność i certyfikacje

Część XVI (roz. 120–125): Scenariusze operacyjne

Część XVII (roz. 126–131): Załączniki normatywne

Łączna objętość: ~327 000 słów | Format: Markdown 3.0

2.1 Kompleksowy podręcznik produktu, architektury, bezpieczeństwa, operacji i wdrożeń

Wersja 3.0.0-draft | Kwiecień 2026 | POUFNE
partnerów Właściciel dokumentu: Architekt Główny SYLION

CZĘŚĆ I — FUNDAMENT DOKUMENTU

Rozdział 1. Wprowadzenie i cele dokumentu

1.1 Cel i zakres dokumentu

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Dev | Infra | SOC | Compliance | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 1.2, 1.3, 1.6, 1.7, 2.1–2.9

Niniejsza Księga Systemu SYLION 3.0 stanowi centralny, normatywny dokument referencyjny opisujący architekturę, zasady bezpieczeństwa, model operacyjny oraz wytyczne wdrożeniowe platformy SYLION — bezpiecznego systemu komunikacji i pracy zdalnej opartego na modelu Thin Client, architekturze Zero Trust oraz mikrosegmentacji per-operator.

Cel dokumentu jest trojaki. Po pierwsze, księga definiuje baseline produkcyjny — minimalny zestaw wymagań architektonicznych, kryptograficznych, operacyjnych i compliance'owych, które musi spełniać każde wdrożenie SYLION oznaczone jako produkcyjne. Po drugie, dokument ustanawia wspólny język pomiędzy wszystkimi interesariuszami: zarządem, architektami, zespołami platformowymi, SOC, compliance, partnerami wdrożeniowymi i klientami enterprise. Po trzecie, księga mapuje decyzje architektoniczne do konkretnych zagrożeń, klas adversary oraz wymagań regulacyjnych, zapewniając pełną identyfikowalność (traceability) pomiędzy ryzykiem a mechanizmem ochronnym.

Zakres dokumentu obejmuje sześć stref bezpieczeństwa systemu SYLION (Strefa 0 — endpointy, Strefa 1 — routery dostępowe, Strefa 2 — bramki G1/G2, Strefa 3 — workloady operatorskie, Strefa 4 — usługi współdzielone, Strefa 5 — płaszczyzna zarządzania) oraz trzy poziomy wdrożeniowe (STANDARD, PRO, STATE/SOVEREIGN). Dokument musi być traktowany jako żywy artefakt — podlega cyklicznej aktualizacji zgodnie z polityką wersjonowania opisaną w Rozdziale 4.

Każdy komponent, protokół lub mechanizm opisany w księdze jest klasyfikowany według poziomu normatywności: [N] Normatywny, [R] Rekomendowany, [O] Opcjonalny, [E] Eksperymentalny lub [A] Autonomiczny. Klasyfikacja ta determinuje, czy dany element wchodzi w skład rdzenia certyfikowalnego, czy stanowi moduł autonomiczny zarządzany przez operatora. Dokument nie zastępuje dokumentacji wykonawczej (runbooki, playbooki, IaC), lecz stanowi dla niej nadrzędne źródło wymagań i ograniczeń architektonicznych.

1.2 Charakter dokumentu: księga systemu vs specyfikacja techniczna

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 1.1, 1.9, 3.1, 3.9

Księga Systemu SYLION 3.0 nie jest specyfikacją techniczną w tradycyjnym rozumieniu — nie stanowi dokumentu implementacyjnego zawierającego sygnatury API, schematy baz danych czy konfiguracje infrastruktury jako kodu (IaC). Jest natomiast dokumentem architektonicznym najwyższego poziomu, który łączy perspektywę biznesową, produktową, architektoniczną, bezpieczeństwa i operacyjną w jeden spójny model referencyjny.

Różnica między księgą systemu a specyfikacją techniczną jest fundamentalna i musi być rozumiana przez wszystkich odbiorców. Specyfikacja techniczna odpowiada na pytanie „jak dokładnie zaimplementować komponent X”. Księga systemu odpowiada na pytania wyższego rzędu: „dlaczego komponent X istnieje”, „jakie zagrożenie adresuje”, „jakie są jego nienaruszalne właściwości bezpieczeństwa”, „jak współgra z pozostałymi elementami systemu” oraz „jakie ryzyka rezydualne pozostają po jego wdrożeniu”.

Charakter dokumentu wynika z ewolucji platformy od koncepcji FORTRESS przez kolejne iteracje SYLION. Doświadczenie z trzema niezależnymi analizami bezpieczeństwa (które ujawniły 5 krytycznych sprzeczności i 12 otwartych luk) wykazało, że fragmentaryczna dokumentacja techniczna — bez nadrzędnego dokumentu spinającego decyzje architektoniczne — prowadzi do niespójności między komponentami, luk w modelu zagrożeń oraz trudności w audycie.

Księga pełni zatem rolę kontraktu architektonicznego: każdy zespół implementacyjny musi wykazać zgodność swojego rozwiązania z wymaganiami księgi, lecz posiada swobodę w wyborze środków realizacji, o ile spełnione są zdefiniowane właściwości bezpieczeństwa (security properties) i nie naruszono granic stref. Dokument jest zaprojektowany tak, aby mógł być przedłożony audytorom, regulatorom i klientom sektora publicznego jako dowód systematycznego podejścia do bezpieczeństwa — stanowi zatem również element portfolio compliance platformy SYLION.

1.3 Zakres merytoryczny: biznes, produkt, architektura, bezpieczeństwo, operacje, wdrożenia

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Dev | Infra | SOC | Compliance | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 1.1, 1.4, 2.1–2.9, 3.1

Zakres merytoryczny Księgi Systemu SYLION 3.0 obejmuje sześć wzajemnie powiązanych domen, z których każda posiada dedykowane rozdziały w dalszych częściach dokumentu. Podział na domeny nie jest przypadkowy — odzwierciedla strukturę decyzyjną organizacji i zapewnia, że każdy interesariusz odnajdzie wymagania i wytyczne adekwatne do swojej roli.

Domena biznesowa obejmuje pozycjonowanie produktu, model tieringu (STANDARD / PRO / STATE/SOVEREIGN), strategię go-to-market, model licencjonowania oraz analizę konkurencyjną ze szczególnym uwzględnieniem Hypori jako najbliższego komercyjnego odpowiednika (model VMI, FedRAMP High, DoD IL5). Domena ta definiuje kontekst rynkowy, w którym operuje SYLION, oraz wymagania regulacyjne poszczególnych segmentów klientów.

Domena produktowa opisuje funkcjonalności platformy z perspektywy użytkownika końcowego i operatora: bezpieczną komunikację opartą na Matrix (z Signal jako degradowanym workloadem kompatybilnościowym), zdalny pulpit w modelu Thin Client (terminal wyświetla wyłącznie piksele i audio, dane rezydują w chmurowym VPS), transfer plików przez CDR ze stagingiem oraz zarządzanie tożsamością.

Domena architektoniczna stanowi rdzeń dokumentu. Opisuje model stref bezpieczeństwa (Strefy 0–5), architekturę Split Gateway (G1 — bramka sieciowa, G2 — broker dostępu), mikrosegmentację per-operator, izolację workloadów w mikroVM Firecracker, infrastrukturę immutable (zniszcz i odbuduj zamiast łączyć) oraz Confidential Computing (AMD SEV-SNP / Intel TDX).

Domena bezpieczeństwa definiuje stos kryptograficzny (HSM/PKI/PQC), protokoły transportowe (IPsec IKEv2 zamiast WireGuard dla zgodności z FIPS/CNSA 2.0), model zagrożeń z klasami adversary, polityki Zero Trust oraz mechanizmy wykrywania i reagowania.

Domena operacyjna obejmuje monitoring, obserwowalność, zarządzanie incydentami, SLA/SLO oraz procesy operacyjne SOC.

Domena wdrożeniowa definiuje procesy onboardingu operatorów, migracji, testów akceptacyjnych oraz utrzymania środowisk.

1.4 Granice dokumentu: czego dokument nie opisuje

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Dev | Infra | Compliance | Partner Wpływ na baseline: Średni Powiązane rozdziały: 1.1, 1.3, 1.9

Precyzyjne zdefiniowanie granic dokumentu jest równie istotne jak określenie jego zakresu. Każdy czytelnik musi rozumieć, jakich informacji nie znajdzie w niniejszej księdze, aby uniknąć fałszywych założeń i właściwie zarządzać oczekiwaniami wobec dokumentu.

Księga Systemu SYLION 3.0 nie opisuje następujących obszarów:

Kod źródłowy i implementacja nisko-poziomowa. Dokument nie zawiera fragmentów kodu, konfiguracji Terraform/Ansible, schematów baz danych ani sygnatur API. Te elementy są zarządzane w repozytoriach kodu i dokumentacji wykonawczej (patrz Rozdział 1.9). Księga definiuje wymagania i ograniczenia, a nie sposób ich realizacji na poziomie kodu.

Dokumentacja użytkownika końcowego. Instrukcje obsługi aplikacji klienckiej, FAQ, materiały szkoleniowe dla użytkowników nie-technicznych oraz dokumentacja UX/UI nie wchodzi w zakres księgi. Są utrzymywane jako odrębne artefakty w systemie zarządzania wiedzą.

Szczegółowe konfiguracje per-operator. Ze względu na architekturę mikrosegmentacji, każdy operator posiada izolowane środowisko z potencjalnie odmienną konfiguracją. Księga definiuje ramy i ograniczenia (guardrails), lecz nie dokumentuje indywidualnych konfiguracji operatorskich — te są zarządzane przez mechanizmy autonomiczne [A] na poziomie operatora.

Wewnętrzne procesy HR, finansowe i korporacyjne. Struktura organizacyjna, budżety, umowy z dostawcami, polityki kadrowe i inne procesy wewnętrzne firmy nie są przedmiotem księgi.

Dokumentacja komponentów open-source stron trzecich. Księga opisuje sposób integracji i wymagania bezpieczeństwa wobec komponentów takich jak Matrix, Firecracker czy IPsec, lecz nie duplikuje ich oficjalnej dokumentacji. Odwołania do dokumentacji upstream są realizowane przez odnośniki.

Plany cenowe i warunki handlowe. Szczegóły cenników, warunki umów SLA z klientami oraz strategię rabatowe są zarządzane poza księgą, choć dokument definiuje techniczne ramy poszczególnych tierów.

1.5 Status dokumentu i poziom dojrzałości

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 1.6, 1.7, 3.3, 4.1, 4.2

Status dokumentu odzwierciedla poziom dojrzałości opisywanych komponentów oraz samej platformy SYLION. Rozróżnienie to jest krytyczne, ponieważ dokument opisuje zarówno elementy produkcyjne, w pełni przetestowane i wdrożone, jak i komponenty będące w fazie projektowania, prototypowania lub ewaluacji.

Księga Systemu SYLION 3.0 przyjmuje następujące poziomy dojrzałości dokumentu:

DRAFT (Szkielet) — wersja robocza podlegająca aktywnym zmianom. Może zawierać niekompletne sekcje, otwarte pytania architektoniczne oznaczone tagiem [OPEN] oraz warianty decyzyjne oczekujące na rozstrzygnięcie. Wersje DRAFT nie mogą być podstawą decyzji wdrożeniowych ani zobowiązań wobec klientów.

REVIEW (Przegląd) — wersja kompletna merytorycznie, przekazana do przeglądu przez właścicieli rozdziałów, architektów bezpieczeństwa i zespół compliance. W fazie REVIEW dokument jest zamrożony pod względem struktury; dopuszczalne są wyłącznie korekty merytoryczne, uzupełnienia brakujących referencji oraz usunięcie niespójności zidentyfikowanych podczas przeglądu.

APPROVED (Zatwierdzona) — wersja zatwierdzona przez Architekta Głównego oraz Komitet Bezpieczeństwa. Stanowi wiążącą referencję dla zespołów implementacyjnych. Zmiany w wersji APPROVED wymagają formalnego procesu zarządzania zmianą (patrz Rozdział 4.4).

SUPERSEDED (Zastąpiona) — wersja historyczna, zastąpiona nowszym wydaniem. Zachowywana w archiwum dla celów audytowych i identyfikowalności decyzji. Nie może być podstawą nowych wdrożeń.

Obecna wersja 3.0.0-draft posiada status DRAFT. Komponenty opisane w dokumencie posiadają zróżnicowany poziom dojrzałości: rdzeń architektoniczny (model stref, Split Gateway, IPsec IKEv2, Matrix, Firecracker) klasyfikowany jest jako dojrzały (wdrożony lub w zaawansowanej fazie wdrożenia). Elementy takie jak pełna integracja PQC (post-quantum cryptography) oraz Confidential Computing z atestacją sprzętową klasyfikowane są jako rozwijane. Funkcje oznaczone tagiem [E] Eksperymentalny (np. niektóre scenariusze federacji Matrix) posiadają status eksploracyjny.

1.6 Zasady interpretacji: „musi”, „powinien”, „może”

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Dev | Infra | SOC | Compliance | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 1.1, 1.7, 3.4, 3.5

Księga Systemu SYLION 3.0 stosuje trójstopniowy system normatywny wzorowany na RFC 2119 (IETF), dostosowany do kontekstu platformy bezpieczeństwa.

Precyzyjne rozumienie tych trzech czasowników modalnych jest warunkiem prawidłowej interpretacji każdego wymagania w dokumencie.

„MUSI” (MUST) — wymaganie bezwzględnie obowiązkowe dla baseline produkcyjnego. Naruszenie wymagania oznaczonego „musi” stanowi blokadę wdrożenia: system nie może zostać dopuszczony do produkcji bez spełnienia tego wymagania. Wymagania „musi” są weryfikowalne — każdemu z nich odpowiada test akceptacyjny, kontrola audytowa lub walidacja automatyczna. Przykład: „Każdy tunel między strefami musi wykorzystywać IPsec IKEv2 z zestawem szyfrów zgodnym z CNSA 2.0.” Odstępstwo od wymagania „musi” wymaga formalnej decyzji Komitetu Bezpieczeństwa, dokumentacji ryzyka rezydualnego oraz planu remediacji z terminem.

„POWINIEN” (SHOULD) — silna rekomendacja, której pominięcie wymaga udokumentowanego uzasadnienia. Odstępstwo od wymagania „powinien” wymaga zatwierdzenia przez architekta odpowiedzialnego za daną strefę oraz wpisu do rejestru odstępstw z uzasadnieniem architektonicznym i śladem audytowym (audit trail). Wymagania „powinien” odzwierciedlają najlepsze praktyki, których wdrożenie jest oczekiwane w typowym scenariuszu, lecz mogą podlegać modyfikacji ze względu na specyfikę wdrożenia, ograniczenia platformowe lub decyzję architektoniczną. Przykład: „Operator powinien włączyć rotację kluczy sesyjnych co 24 godziny.”

„MOŻE” (MAY) — wymaganie warunkowe, którego zastosowanie zależy od poziomu wdrożenia (tier), jurysdykcji, profilu ryzyka operatora lub decyzji biznesowej. Wymagania „może” nie podlegają weryfikacji audytowej w ramach baseline, lecz mogą stać się obowiązkowe dla wyższych tierów (PRO, STATE/SOVEREIGN) lub specyficznych regulacji. Przykład: „Operator może wdrożyć dedykowany HSM on-premises dla zarządzania kluczami głównymi.”

Każde zdanie w księdze zawierające jeden z powyższych czasowników musi być interpretowane ściśle zgodnie z niniejszą definicją. Brak czasownika modalnego oznacza stwierdzenie opisowe lub informacyjne, nie stanowiące wymagania.

1.7 Poziomy normatywności: baseline, premium, state-level, eksperymentalne

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 1.6, 3.4, 3.5, 3.6

System SYLION operuje w modelu wielopoziomowym, w którym zakres wymagań bezpieczeństwa i funkcjonalności rośnie wraz z poziomem wdrożenia. Księga definiuje cztery poziomy normatywności, które mapują się bezpośrednio na tiery produktowe i tagi statusu rozdziałów.

BASELINE (Tier STANDARD) — wymagania obowiązkowe [N]

Baseline stanowi niepodzielny rdzeń bezpieczeństwa platformy. Obejmuje: architekturę Zero Trust z modelem stref 0–5, Split Gateway (G1/G2), IPsec IKEv2 jako protokół transportowy, Matrix jako rdzeń komunikacyjny, izolację workloadów w Firecracker microVM, mikrosegmentację per-operator, infrastrukturę immutable, stos kryptograficzny oparty na HSM z PKI oraz transfer plików przez CDR ze stagingiem. Każde wdrożenie produkcyjne SYLION musi spełniać 100% wymagań baseline. Nie istnieje mechanizm „częściowej zgodności” z baseline — niespełnienie dowolnego wymagania [N] blokuje certyfikację wdrożenia.

PREMIUM (Tier PRO) — wymagania rozszerzone [R] + [N]

Tier PRO obejmuje pełny baseline oraz dodatkowe mechanizmy oznaczone tagiem [R]: zaawansowaną obserwowalność (distributed tracing, SIEM tier-2), rozszerzone SLA (RPO/RTO), dedykowane instancje HSM per-operator, zaawansowane polityki retencji oraz integracje z systemami SOAR klienta. Wymagania [R] w kontekście tieru PRO stają się de facto obowiązkowe — ich pominięcie degraduje wdrożenie do poziomu STANDARD.

STATE/SOVEREIGN (Tier STATE) — wymagania suwerenności [N] + [R] + specyficzne [O]

Najwyższy tier adresuje wymagania sektora publicznego, obronnego i regulowanego. Obejmuje pełny zakres PRO uzupełniony o: Confidential Computing z atestacją sprzętową (AMD SEV-SNP / Intel TDX), rezydencję danych w określonej jurysdykcji, pełną integrację PQC (post-quantum cryptography) zgodną z CNSA 2.0, dedykowaną infrastrukturę fizyczną (bare-metal), certyfikację według standardów krajowych oraz formalne zarządzanie łańcuchem dostaw (supply chain security).

EKSPERYMENTALNE [E]

Komponenty oznaczone tagiem [E] znajdują się w fazie R&D i nie mogą być wdrażane w środowiskach produkcyjnych. Służą do ewaluacji technologii, prototypowania i testów penetracyjnych w środowiskach izolowanych.

1.8 Relacja dokumentu do roadmapy produktu

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Dev | Partner Wpływ na baseline: Średni Powiązane rozdziały: 1.5, 3.3, 4.1, 4.3

Księga Systemu i roadmapa produktu to dwa odrębne, lecz ściśle powiązane artefakty. Zrozumienie ich relacji jest kluczowe dla uniknięcia dwóch typowych pułapek: traktowania księgi jako roadmapy (co prowadzi do wdrażania niegotowych komponentów) lub traktowania roadmapy jako architektury (co prowadzi do implementacji bez fundamentu bezpieczeństwa).

Zasada pierwszeństwa: Księga systemu ma pierwszeństwo nad roadmapą w zakresie wymagań bezpieczeństwa i architektonicznych. Roadmapa nie może planować wdrożenia funkcjonalności, która naruszałaby wymagania [N] baseline. Jeżeli planowana funkcja wymaga modyfikacji baseline, musi to zostać najpierw zaproponowane jako zmiana w księdze i zatwierdzone w procesie opisanym w Rozdziale 4.6.

Zasada synchronizacji: Roadmapa produktu powinna być synchronizowana z księgą w cyklach kwartalnych. Każdy nowy komponent wprowadzany przez roadmapę musi posiadać przypisany tag normatywności ([N], [R], [O], [E], [A]) oraz wstępną analizę wpływu na model stref i baseline. Architekt Główny powinien uczestniczyć w przeglądach roadmapy, aby zapewnić spójność planów rozwojowych z architekturą systemu.

Zasada dojrzałości: Komponenty w roadmapie przechodzą ścieżkę dojrzałości: [E] Eksperymentalny → [O] Opcjonalny → [R] Rekomendowany → [N] Normatywny. Przejście między poziomami wymaga spełnienia kryteriów opisanych w Rozdziale 3.3. Roadmapa może planować komponenty na dowolnym poziomie dojrzałości, lecz ich promocja do wyższego poziomu jest decyzją architektoniczną, nie produktową.

Mechanizm oznaczania: Elementy księgi, które opisują funkcjonalności planowane, lecz jeszcze niewdrożone, muszą być oznaczone tagiem [ROADMAP: Qn/YYYY] z przewidywanym kwartałem realizacji. Tag ten jest usuwany po wdrożeniu i walidacji komponentu. Obecność tagu [ROADMAP] oznacza, że dany fragment księgi ma charakter projektowy, nie normatywny — nie może stanowić podstawy zobowiązań wobec klientów.

1.9 Relacja dokumentu do dokumentacji wykonawczej

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 1.2, 1.4, 3.1, 3.9

Dokumentacja wykonawcza (runbooki, playbooki, konfiguracje IaC, schematy CI/CD, specyfikacje API, diagramy wdrożeniowe) stanowi warstwę realizacyjną, która musi być zgodna z wymaganiami i ograniczeniami zdefiniowanymi w Księdze Systemu. Relacja między tymi dwoma poziomami dokumentacji jest hierarchiczna i jednokierunkowa: księga definiuje „co” i „dlaczego”, dokumentacja wykonawcza definiuje „jak”.

Hierarchia dokumentacji SYLION:

Księga Systemu (niniejszy dokument) — wymagania architektoniczne, bezpieczeństwa i operacyjne najwyższego poziomu.

Architecture Decision Records (ADR) — udokumentowane decyzje architektoniczne z kontekstem, rozważanymi wariantami i uzasadnieniem wyboru. Każdy ADR musi wskazywać sekcję księgi, do której się odnosi.

Specyfikacje techniczne — szczegółowe opisy komponentów, protokołów, interfejsów i schematów danych. Specyfikacja techniczna nie może definiować wymagań sprzecznych z księgą.

Runbook i playbooki — procedury operacyjne krok po kroku, w tym procedury awaryjne (incident response), procedury odtworzeniowe (disaster recovery) i procedury rotacji kluczy.

Konfiguracje IaC — kod infrastruktury (Terraform, Ansible, Helm) implementujący wymagania architektoniczne w konkretnym środowisku.

Zasada spójności: Każda dokumentacja wykonawcza musi zawierać sekcję „Referencja do Księgi Systemu” wskazującą numery rozdziałów i podrozdziałów, z których wynikają realizowane wymagania. W przypadku wykrycia niespójności między dokumentacją wykonawczą a księgą, obowiązuje zasada: księga ma rację, chyba że niespójność wynika z formalnie zatwierdzonego odstępstwa (patrz Rozdział 4.4).

Zasada aktualności: Dokumentacja wykonawcza musi być aktualizowana w ciągu 30 dni kalendarzowych od opublikowania nowej wersji księgi, jeżeli zmiana dotyczy rozdziałów referencjonowanych przez daną dokumentację. Właściciele dokumentacji wykonawczej muszą być uwzględnieni w liście dystrybucyjnej zmian księgi.

Automatyzacja walidacji: Tam gdzie jest to technicznie wykonalne, zgodność konfiguracji IaC z wymaganiami księgi powinna być walidowana automatycznie (policy-as-code, np. OPA/Rego lub Sentinel). Reguły walidacyjne powinny być utrzymywane w tym samym repozytorium co konfiguracje IaC.

1.10 Jak korzystać z księgi w praktyce

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Dev | Infra | SOC | Compliance | Partner | Klient Wpływ na baseline: Niski Powiązane rozdziały: 1.1–1.9, 2.1–2.9

Księga Systemu SYLION 3.0 jest obszernym dokumentem zaprojektowanym dla wielości odbiorców o zróżnicowanych potrzebach. Niniejsza sekcja zawiera praktyczne wskazówki dotyczące efektywnego korzystania z dokumentu w codziennej pracy.

Ścieżka lektury dla nowego czytelnika: Nowy członek zespołu powinien rozpocząć od Rozdziału 1 (wprowadzenie i zasady interpretacji), następnie przejść do Rozdziału 2 w celu zidentyfikowania swojej roli czytelniczej, a następnie korzystać z matrycy w sekcji 2.9, aby zidentyfikować rozdziały priorytetowe dla swojej roli. Lektura liniowa całego dokumentu jest zalecana wyłącznie dla architektów i liderów bezpieczeństwa.

Nawigacja tematyczna: Każdy podrozdział zawiera nagłówek metadanych wskazujący status normatywny, docelowego odbiorcę, wpływ na baseline oraz powiązane rozdziały. Czytelnik może korzystać z pól „Powiązane rozdziały” jako systemu nawigacji krzyżowej, śledząc zależności między komponentami bez konieczności czytania całości.

Filtrowanie według statusu: Czytelnik zainteresowany wyłącznie wymaganiami obowiązkowymi powinien filtrować rozdziały oznaczone [N] Normatywny. Czytelnik przygotowujący wdrożenie PRO powinien uwzględnić [N] + [R]. Zespoły R&D powinny zwrócić uwagę na sekcje [E] Eksperymentalny.

Wykorzystanie w audycie: Podczas audytów wewnętrznych i zewnętrznych, księga stanowi referencję dla zakresu audytu. Audytor powinien zweryfikować, czy wymagania [N] są spełnione w 100%, wymagania [R] są spełnione lub posiadają udokumentowane odstępstwa, a wymagania [O] i [E] nie zostały błędnie wdrożone jako produkcyjne bez odpowiedniej promocji statusu.

Wykorzystanie w planowaniu sprintów: Zespoły deweloperskie powinny traktować wymagania księgi jako źródło kryteriów akceptacji (acceptance criteria) dla zadań w backlogu. Każde zadanie implementacyjne powinno posiadać referencję do odpowiedniego rozdziału księgi, co zapewnia identyfikowalność wymagań (requirements traceability).

Zgłaszanie niejasności: Wszelkie niejasności interpretacyjne powinny być zgłaszane do właściciela danego rozdziału (patrz Rozdział 4.7) za pośrednictwem dedykowanego kanału w systemie komunikacji wewnętrznej. Nierozstrzygnięte niejasności muszą być eskalowane do Architekta Głównego.

Rozdział 2. Odbiorcy i role czytelnicze

2.1 Zarząd i właściciele produktu

Status: [R] Rekomendowany Odbiorca: Zarząd Wpływ na baseline: Średni Powiązane rozdziały: 1.1, 1.3, 1.8, 2.9

Zarząd i właściciele produktu (Product Owners) stanowią kluczową grupę odbiorców Księgi Systemu, choć ich sposób korzystania z dokumentu różni się fundamentalnie od pozostałych ról. Zarząd nie potrzebuje rozumieć szczegółów implementacyjnych protokołów kryptograficznych czy konfiguracji Firecracker — potrzebuje natomiast jasnego obrazu: jakie ryzyka adresuje platforma, jakie zobowiązania wynikają z baseline, jakie decyzje architektoniczne mają implikacje biznesowe oraz jakie są ograniczenia systemu.

Kluczowe rozdziały dla zarządu: Część I (fundament dokumentu), rozdziały dotyczące pozycjonowania produktu i tieringu, rozdziały dotyczące modelu zagrożeń na poziomie strategicznym (klasy adversarzy, scenariusze naruszenia), rozdziały dotyczące compliance i certyfikacji oraz rozdziały dotyczące SLA/SLO.

Perspektywa decyzyjna: Zarząd powinien korzystać z księgi jako źródła informacji dla następujących typów decyzji: (a) priorytety inwestycyjne — które komponenty wymagają nakładów, aby przejść z [E] do [N]; (b) ekspozycja na ryzyko — jakie ryzyka rezydualne pozostają i jaki jest ich wpływ biznesowy; (c) zobowiązania wobec klientów — jakie gwarancje bezpieczeństwa platforma może oferować na poszczególnych tierach; (d) strategia certyfikacyjna — jakie certyfikacje są osiągalne w jakim horyzoncie czasowym.

Zasada odpowiedzialności: Zarząd musi być świadomy, że zatwierdzenie wdrożenia na danym tierze oznacza akceptację pełnego zestawu wymagań tego tieru. Degradacja wymagań bez formalnego procesu odstępstwa (waiver) stanowi naruszenie polityki bezpieczeństwa organizacji i może mieć konsekwencje regulacyjne, szczególnie w kontekście klientów sektora publicznego.

Format komunikacji: Dla zarządu powinny być przygotowywane kwartalne briefy bezpieczeństwa (Security Briefings) extrahowane z księgi, zawierające podsumowanie zmian, nowe ryzyka, postęp certyfikacyjny oraz kluczowe decyzje wymagające eskalacji. Format briefu jest definiowany w dokumentacji operacyjnej.

2.2 Architekci systemowi i architekci bezpieczeństwa

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 1.2, 1.6, 1.9, 2.9, 3.9

Architekci systemowi i architekci bezpieczeństwa stanowią główną grupę odbiorców Księgi Systemu. Dokument w całości jest dla nich obowiązkową lekturą — są jedyną rolą, dla której zalecana jest pełna lektura liniowa. Architekci są odpowiedzialni za translację wymagań księgi na decyzje projektowe, walidację zgodności implementacji z baseline oraz identyfikację nowych ryzyk wymagających aktualizacji dokumentu.

Obowiązki architekta wobec księgi:

Znajomość pełna — architekt musi znać treść wszystkich rozdziałów dotyczących jego domeny (architektura, bezpieczeństwo lub obie) oraz rozumieć zależności między strefami.

Strażnik spójności — każda propozycja zmiany architektonicznej musi być weryfikowana pod kątem zgodności z wymaganiami [N] i [R] księgi. Architekt musi identyfikować i dokumentować przypadki, w których proponowana zmiana wymagałaby modyfikacji baseline.

Autor ADR — decyzje architektoniczne podjęte w trakcie implementacji muszą być dokumentowane jako Architecture Decision Records z referencją do odpowiednich sekcji księgi.

Recenzent — architekci bezpieczeństwa muszą uczestniczyć w procesie recenzji każdej nowej wersji księgi (patrz Rozdział 4.6).

Właściciel stref — każdej strefie bezpieczeństwa (0–5) musi być przypisany architekt odpowiedzialny (zone owner), który jest pierwszym punktem kontaktowym dla pytań dotyczących wymagań danej strefy.

Perspektywa architekta bezpieczeństwa: Architekt bezpieczeństwa powinien szczególnie skupić się na: modelu zagrożeń i klasach adwersarzy, stosie kryptograficznym (HSM/PKI/PQC), politykach Zero Trust, mechanizmach izolacji (Firecracker, mikrosegmentacja, Confidential Computing), procedurach reagowania na incydenty oraz analizie porównawczej z rozwiązaniami konkurencyjnymi (w szczególności Hypori).

Narzędzia architekta: Architekt powinien utrzymywać mapping: wymaganie księgi → ADR → implementacja → test walidacyjny. Mapping ten stanowi dowód identyfikowalności wymagań i jest kluczowy dla procesów audytowych i certyfikacyjnych.

2.3 Zespoły platformowe, DevOps, SRE i infrastruktura

Status: [N] Normatywny Odbiorca: Infra Wpływ na baseline: Wysoki Powiązane rozdziały: 1.9, 2.2, 2.9, 3.6

Zespoły platformowe, DevOps, SRE (Site Reliability Engineering) i infrastruktura stanowią grupę odpowiedzialną za fizyczną i logiczną realizację wymagań architektonicznych zdefiniowanych w księdze. Ich perspektywa jest operacyjna — potrzebują jasnych, weryfikowalnych wymagań, które mogą przełożyć na konfigurację infrastruktury, pipeline CI/CD, polityki sieciowe i procedury operacyjne.

Kluczowe obszary dla zespołów platformowych:

Infrastruktura immutable. Księga definiuje zasadę „zniszcz i odbuduj, nie łataj” jako wymaganie [N] baseline. Zespoły infrastrukturalne muszą zapewnić, że każdy komponent w Strefach 2–5 może zostać zniszczony i odbudowany z deklaratywnego opisu (IaC) bez utraty danych krytycznych (dane są oddzielone od compute). Pipeline CI/CD musi obsługiwać rolling replacement zamiast in-place update.

Model stref sieciowych. Implementacja sześciu stref bezpieczeństwa (0–5) wymaga precyzyjnej konfiguracji segmentacji sieciowej, reguł firewalla, polityk routingu oraz tuneli IPsec IKEv2 między strefami. Zespół infrastrukturalny musi zapewnić, że ruch między strefami jest wymuszany przez bramki G1/G2 zgodnie z modelem Split Gateway.

Izolacja workloadów. Uruchamianie workloadów operatorskich w mikroVM Firecracker wymaga specjalistycznej konfiguracji hosta, zarządzania obrazami VM, alokacji zasobów (CPU, pamięć, I/O) oraz monitoringu per-VM. Zespół musi zapewnić, że izolacja jest egzekwowana sprzętowo (nie wyłącznie softwarowo) i że mechanizmy Confidential Computing (AMD SEV-SNP / Intel TDX) są poprawnie skonfigurowane dla tieru STATE/SOVEREIGN.

Obserwabilność i monitoring. Zespoły SRE muszą zapewnić pełną obserwabilność wszystkich stref, z uwzględnieniem wymagań bezpieczeństwa — logi nie mogą zawierać danych wrażliwych operatorów, metryki muszą być segregowane per-operator, a alerting musi respektować granice mikrosegmentacji.

Zarządzanie sekretami i kluczami. Integracja z HSM, zarządzanie certyfikatami PKI, rotacja kluczy oraz przygotowanie do migracji PQC — to obowiązki zespołu infrastrukturalnego realizowane pod nadzorem architekta bezpieczeństwa.

2.4 SOC, IR, compliance, audyt

Status: [N] Normatywny Odbiorca: SOC | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 1.6, 1.7, 2.2, 2.9

Zespoły Security Operations Center (SOC), Incident Response (IR), compliance i audytu korzystają z księgi jako z referencji normatywnej definiującej: co musi być monitorowane, jakie zdarzenia stanowią incydent, jakie procedury muszą być wdrożone, jakie dowody muszą być zbierane oraz jakie regulacje i standardy muszą być spełnione.

SOC i Incident Response:

Księga definiuje model zagrożeń z klasami adwersarzy — od oportunistycznych (skrypt kiddies, ransomware-as-a-service) przez zaawansowane (APT, państwowe) do klasy najwyższej (adwersarze z dostępem do supply chain i zasobami państwowymi). Dla każdej klasy adwersarza księga definiuje oczekiwane scenariusze ataku oraz wymagane mechanizmy detekcji i reagowania. Zespół SOC musi mapować swoje reguły detekcji (SIEM, SOAR, EDR) na scenariusze zdefiniowane w księdze.

Procedury IR muszą uwzględniać specyfikę architektury SYLION: infrastruktura immutable oznacza, że po incydencie zainfekowane komponenty są niszczone (nie czyszczone), dane forensic muszą być zebrane przed zniszczeniem, a odbudowa następuje z czystego obrazu. Mikrosegmentacja per-operator oznacza, że blast radius incydentu jest ograniczony do jednego operatora — procedury IR muszą to uwzględniać.

Compliance i audyt:

Zespół compliance korzysta z księgi jako mapy kontroli bezpieczeństwa (security controls). Każde wymaganie [N] stanowi kontrolę, która musi być zweryfikowana i udokumentowana. Księga powinna być podstawą do tworzenia macierzy mapowania na standardy i regulacje (np. ISO 27001, SOC 2, NIS2, DORA, FedRAMP, CC — Common Criteria).

Audytory (wewnętrzni i zewnętrzni) powinni korzystać z księgi jako z definicji zakresu audytu. Wymagania [N] podlegają pełnemu audytowi, wymagania [R] podlegają weryfikacji spełnienia lub udokumentowania odstępstwa, elementy [O] i [E] podlegają weryfikacji, czy nie zostały wdrożone poza kontrolą zmian. Księga

stanowi dowód podejścia security-by-design, co jest wymagane przez wiele regulacji sektora publicznego i finansowego.

2.5 Deweloperzy backend, frontend, integracje, SDK

Status: [R] Rekomendowany Odbiorca: Dev Wpływ na baseline: Średni Powiązane rozdziały: 1.9, 2.2, 2.3, 2.9

Deweloperzy nie są bezpośrednimi odbiorcami większości treści architektonicznych książki — ich głównym interfejsem jest dokumentacja wykonawcza (specyfikacje API, SDK, wzorce integracyjne). Jednakże zrozumienie fundamentalnych zasad architektonicznych SYLION jest niezbędne, aby uniknąć implementacji podważających bezpieczeństwo systemu.

Deweloperzy backend:

Muszą rozumieć model stref bezpieczeństwa, ponieważ każdy serwis backendowy działa w konkretnej strefie i podlega jej regułom. Komunikacja między strefami jest ściśle regulowana — serwis w Strefie 3 (workloady operatorskie) nie może bezpośrednio komunikować się z serwisem w Strefie 5 (management plane) z pominięciem bramek. Deweloperzy muszą projektować API i serwisy z uwzględnieniem granic stref i zasady least privilege.

Muszą również rozumieć zasadę infrastruktury immutable: serwisy nie mogą zakładać persystencji stanu lokalnego, muszą być bezstanowe (stateless) lub przechowywać stan w dedykowanych, replikowanych magazynach danych. Restarty i przebudowy mogą nastąpić w dowolnym momencie.

Deweloperzy frontend:

Muszą rozumieć model Thin Client: aplikacja kliencka renderuje wyłącznie piksele i audio otrzymywane z VPS. Nie wykonuje lokalnie logiki biznesowej, nie przechowuje danych wrażliwych i nie posiada bezpośredniego dostępu do zasobów operatorskich. Frontend musi implementować weryfikację integralności sesji, obsługę rozłączeń (graceful degradation) oraz bezpieczne zarządzanie tokenami sesyjnymi.

Deweloperzy integracji i SDK:

Muszą szczegółowo rozumieć model Split Gateway (G1/G2), ponieważ każda integracja zewnętrzna przechodzi przez bramkę G2 (broker dostępu). SDK musi implementować pełny flow uwierzytelniania i autoryzacji zdefiniowany w księdze, obsługiwać rotację certyfikatów oraz respektować limity rate-limiting i throttling zdefiniowane per-tier.

Obowiązkowe minimum dla każdego dewelopera: Rozdziały dotyczące modelu stref, zasad Zero Trust, zasad komunikacji między strefami, wymagań kryptograficznych dla danych w transzycie i w spoczynku, oraz polityki logowania (co może, a czego nie może znaleźć się w logach — ze szczególnym uwzględnieniem danych operatorskich i PII).

2.6 Partnerzy wdrożeniowi i integratorzy

Status: [R] Rekomendowany Odbiorca: Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 1.7, 2.7, 2.9

Partnerzy wdrożeniowi i integratorzy stanowią grupę odbiorców, która musi rozumieć SYLION wystarczająco głęboko, aby bezpiecznie wdrożyć platformę u klienta końcowego, lecz jednocześnie nie wymaga pełnej wiedzy o wewnętrznych mechanizmach implementacyjnych. Dla tej grupy księga pełni rolę kontraktu interfejsowego — definiuje, co partner może konfigurować, czego nie może zmieniać i jakie są granice autonomii wdrożeniowej.

Model odpowiedzialności partnera:

Partner wdrożeniowy musi operować w ramach zdefiniowanych przez księgę guardrails. W szczególności:

Konfiguracja operatorska [A] — partner może konfigurować elementy oznaczone tagiem [A] Autonomiczny (np. polityki dostępu operatora, konfiguracja integracji z systemami klienta, parametryzacja retencji danych w ramach dozwolonych zakresów).

Parametryzacja tieru — partner może aktywować lub dezaktywować funkcje zgodne z zakupionym tierem (STANDARD/PRO/STATE), lecz nie może modyfikować wymagań baseline [N].

Testy akceptacyjne — partner musi przeprowadzić testy akceptacyjne wdrożenia zgodnie z checklistą zdefiniowaną w księdze dla danego tieru. Wyniki testów stanowią warunek formalnej akceptacji wdrożenia.

Certyfikacja partnerów:

Księga definiuje trzy poziomy certyfikacji partnerskiej: (a) Partner Implementacyjny (uprawnienia do wdrożeń STANDARD), (b) Partner Zaawansowany (uprawnienia do wdrożeń PRO), (c) Partner Sovereign (uprawnienia do wdrożeń STATE/SOVEREIGN, wymaga dodatkowej weryfikacji bezpieczeństwa). Każdy poziom wymaga znajomości odpowiednich rozdziałów książki, potwierdzonej egzaminem certyfikacyjnym.

Ograniczenia partnera: Partner nie może: modyfikować konfiguracji rdzenia certyfikowalnego, dezaktywować mechanizmów [N] baseline, uzyskiwać dostępu do płaszczyzny zarządzania (Strefa 5) poza dedykowanym interfejsem partnerskim, ani wdrażać komponentów [E] Eksperymentalnych w środowiskach produkcyjnych klienta.

Kanał eskalacji: W przypadku wykrycia przez partnera sytuacji, w której wymagania klienta są sprzeczne z wymaganiami książki, partner musi eskalować do zespołu architektonicznego SYLION za pośrednictwem dedykowanego kanału partnerskiego. Samodzielne wprowadzanie odstępstw jest niedopuszczalne.

2.7 Klienci enterprise, regulated i public sector

Status: [R] Rekomendowany Odbiorca: Klient Wpływ na baseline: Średni Powiązane rozdziały: 1.7, 2.6, 2.9

Klienci enterprise, podmioty regulowane (sektor finansowy, telekomunikacyjny, energetyczny) oraz sektor publiczny (administracja rządowa, siły zbrojne, służby specjalne) stanowią docelowych użytkowników platformy SYLION. Ich perspektywa na księgę jest zorientowana na: gwarancje bezpieczeństwa, zgodność regulacyjną, audytowalność oraz zakres kontroli nad środowiskiem.

Klienci enterprise (STANDARD/PRO):

Dla klientów enterprise kluczowe są rozdziały dotyczące: modelu tieringu i zakresu funkcjonalności na poszczególnych poziomach, SLA/SLO (dostępność, wydajność, czas reakcji), modelu izolacji (jak ich dane są oddzielone od danych innych operatorów), procedur onboardingu i offboardingu, integracji z istniejącą

infrastrukturą (SSO, SIEM, DLP) oraz modelu odpowiedzialności współdzielonej (shared responsibility model). Klient enterprise powinien otrzymać wyciąg z księgi (Customer Security Whitepaper) dostosowany do jego poziomu uprawnień informacyjnych.

Klienci regulowani (PRO/STATE):

Podmioty regulowane potrzebują dodatkowej warstwy informacji: mapowania kontroli SYLION na wymagania regulacyjne (NIS2, DORA, PCI DSS, HIPAA — w zależności od jurysdykcji), dokumentacji certyfikacyjnej, raportów z testów penetracyjnych (w zakresie dozwolonym przez politykę ujawniania), oraz szczegółów dotyczących rezydencji danych i przetwarzania danych osobowych (GDPR). Księga stanowi dla regulatora dowód, że platforma jest projektowana z uwzględnieniem wymagań bezpieczeństwa od fundamentów (security-by-design).

Sektor publiczny i obronny (STATE/SOVEREIGN):

Klienci z sektora publicznego i obronnego mają najwyższe wymagania. Rozdziały dotyczące: Confidential Computing (AMD SEV-SNP / Intel TDX), pełnej suwerenności danych, zgodności z CNSA 2.0, kryptografii postquantumowej, atestacji sprzętowej, certyfikacji Common Criteria oraz dedykowanej infrastruktury fizycznej są dla nich krytyczne. Analiza porównawcza z Hypori (VMI-based, FedRAMP High, DoD IL5) powinna być udostępniana tej grupie klientów jako element pozycjonowania SYLION na tle rozwiązań z potwierdzonym track recordem w środowiskach obronnych.

Niezależnie od segmentu, klient nie powinien otrzymywać pełnej księgi — udostępniane są wyciągi odpowiednie do tieru i poziomu uprawnień, zatwierdzone przez zespół compliance.

2.8 Odbiorcy szkoleniowi i operacyjni

Status: [R] Rekomendowany Odbiorca: Zarząd | Dev | Infra | SOC | Partner Wpływ na baseline: Niski Powiązane rozdziały: 1.10, 2.1–2.7, 2.9

Odbiorcy szkoleniowi stanowią specyficzną grupę, która korzysta z księgi nie jako z dokumentu referencyjnego, lecz jako ze źródła materiału dydaktycznego. Do tej kategorii należą: nowi członkowie zespołu przechodzący onboarding, uczestnicy programów certyfikacyjnych partnerskich, zespoły operacyjne klienta odpowiedzialne za codzienną administrację oraz trenerzy wewnętrzni i zewnętrzni.

Programy szkoleniowe oparte na księdze:

Księga stanowi bazę merytoryczną dla następujących ścieżek szkoleniowych:

Onboarding techniczny SYLION — szkolenie obowiązkowe dla każdego nowego członka zespołu technicznego. Obejmuje: architekturę stref, model Thin Client, Split Gateway, zasady Zero Trust, model normatywny (musi/powinien/może) oraz podstawy stosu kryptograficznego. Czas trwania: 2 dni. Źródło: Rozdziały 1, 5–8 (architektura i bezpieczeństwo).

Szkolenie SOC/IR SYLION — szkolenie dla analityków SOC i zespołów reagowania na incydenty. Obejmuje: model zagrożeń, klasy adversarzy, scenariusze ataku i obrony, procedury forensic w infrastrukturze immutable, specyfikę mikrosegmentacji w kontekście incydentów. Czas trwania: 3 dni. Źródło: Rozdziały dotyczące bezpieczeństwa i operacji.

Certyfikacja partnerska — trzypoziomowy program certyfikacyjny (Implementacyjny / Zaawansowany / Sovereign) z egzaminem opartym na wiedzy z księgi. Materiały szkoleniowe muszą być zgodne z aktualną wersją księgi; aktualizacja materiałów musi nastąpić w ciągu 60 dni od publikacji nowej wersji.

Szkolenie operacyjne klienta — szkolenie dla administratorów po stronie klienta. Obejmuje wyłącznie elementy [A] Autonomiczne, które klient może samodzielnie konfigurować w ramach swojego tieru.

Zasada aktualności materiałów: Materiały szkoleniowe muszą zawierać informację o wersji księgi, na której są oparte. Szkolenia prowadzone na podstawie nieaktualnej wersji księgi (różnica > 1 wersja główna) muszą być oznaczone jako wymagające aktualizacji. Trenerzy muszą uczestniczyć w przeglądach zmian (changelog review) po każdej publikacji nowej wersji.

2.9 Matryca: rozdziały vs role czytelnicze

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Dev | Infra | SOC | Compliance | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 2.1–2.8

Poniższa matryca definiuje rekomendowany zakres lektury dla poszczególnych ról czytelniczych. Oznaczenia: [O] — obowiązkowe (musi przeczytać), [Z] — zalecane (powinien przeczytać), [I] — informacyjne (może przeczytać w razie potrzeby), [—] — poza zakresem roli.

Rozdział / Obszar	Zarząd	Architekt	Dev	Infra/SRE	SOC/IR	Compliance	Partner	Klient
Cz. I: Fundament dokumentu (R. 1–4)	O	O	Z	Z	Z	O	O	I
Pozycjonowanie i tiering	O	O	I	I	I	O	O	O
Model zagrożeń (strategiczny)	O	O	Z	Z	O	O	Z	Z
Model zagrożeń (taktyczny)	I	O	Z	Z	O	Z	I	—
Architektura stref 0–5	Z	O	O	O	O	Z	O	I
Split Gateway (G1/G2)	I	O	Z	O	Z	I	O	I
Stos kryptograficzny (HSM/PKI/PQC)	I	O	Z	O	Z	O	Z	I
IPsec IKEv2 / transport	—	O	I	O	Z	I	Z	—
Matrix / komunikacja	I	O	O	Z	Z	I	O	Z
Firecracker / izolacja	—	O	Z	O	Z	I	Z	—
Confidential Computing	I	O	I	O	Z	O	Z	Z
Infrastruktura immutable	—	O	Z	O	Z	I	Z	—
CDR / transfer plików	I	O	Z	Z	Z	Z	O	Z
Monitoring i obserwowalność	I	O	Z	O	O	Z	Z	I

SLA/SLO	O	O	I	O	I	O	O	O
Compliance i certyfikacje	O	O	I	I	Z	O	O	O
Procedury operacyjne	I	Z	I	O	O	Z	O	I
Wdrożenia i onboarding	Z	Z	I	O	I	Z	O	Z

Interpretacja matrycy: Matryca ma charakter rekomendacyjny [R], z wyjątkiem kolumny Architekt, gdzie większość pozycji jest oznaczona jako obowiązkowe [O] — co odzwierciedla wymóg pełnej znajomości systemu przez architektów (patrz sekcja 2.2). Klient otrzymuje jedynie wyciąg z księgi odpowiedni do swojego tieru, więc kolumna „Klient” odnosi się do udostępnionych fragmentów. Partner powinien traktować pozycje [O] jako warunek certyfikacji partnerskiej.

Rozdział 3. Metodologia tworzenia księgi

3.1 Źródła wejściowe i baza analityczna

Status: [N] Normatywny Odbiorca: Architekt | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 1.1, 1.2, 3.2, 3.3, 4.3

Księga Systemu SYLION 3.0 nie powstała w próżni — jest syntezą wielu źródeł wejściowych, które zostały poddane systematycznej analizie, walidacji krzyżowej i konsolidacji. Transparentność co do źródeł jest wymaganiem audytowym i elementem budowania zaufania do dokumentu.

Źródła wejściowe pierwszego rzędu (primary sources):

Dokumentacja koncepcyjna FORTRESS — oryginalny dokument projektowy poprzednika SYLION, zawierający pierwotną wizję architektury bezpiecznej komunikacji opartej na WireGuard i Signal. Stanowi kontekst historyczny i źródło lekcji wyciągniętych (lessons learned).

Dokumentacja SYLION v1/v2 — iteracyjne rozwinięcie koncepcji FORTRESS, wprowadzające Split Gateway, model stref i mikrosegmentację. Dokumenty te zawierają ewolucję decyzji architektonicznych od koncepcji do realizacji.

Trzy niezależne analizy bezpieczeństwa — przeprowadzone z wykorzystaniem różnych metodologii (analiza Claude, analiza Gemini, dokument łatania podatności). Analizy te zidentyfikowały 5 krytycznych sprzeczności i 12 otwartych luk w poprzednich wersjach dokumentacji, co bezpośrednio wpłynęło na kształt SYLION 3.0.

Requirements Specification Document (RSD) — formalny dokument wymagań produktowych i bezpieczeństwa.

Źródła wejściowe drugiego rzędu (secondary sources):

Analiza takedownów platform encrypted — studia przypadków EncroChat, Sky ECC, ANOM, Ghost i MATRIX, które dostarczyły empirycznych danych o wektorach ataku wykorzystywanych przez agencje ścigania i służby wywiadowcze.

Analiza konkurencyjna — ze szczególnym uwzględnieniem Hypori (VMI-based, FedRAMP High, DoD IL5) jako najbliższego komercyjnego analogu modelu Thin Client.

Standardy i frameworki referencyjne — NIST SP 800-207 (Zero Trust), CNSA 2.0, FIPS 140-3, Common Criteria, ISO 27001/27002, NIS2, DORA.

Publikacje akademickie i branżowe — dotyczące Confidential Computing, kryptografii postquantumowej, mikrowirtualizacji (Firecracker) oraz protokołu Matrix.

3.2 Metoda scalania materiałów FORTRESS, SYLION i RSD

Status: [N] Normatywny Odbiorca: Architekt | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 3.1, 3.3, 4.3

Scalenie materiałów z trzech głównych linii dokumentacyjnych (FORTRESS, SYLION v1/v2, RSD) w spójną Księgę Systemu 3.0 wymagało zastosowania systematycznej metody zapewniającej: eliminację sprzeczności, zachowanie identyfikowalności decyzji oraz przejrzystość w zakresie ewolucji wymagań.

Etap 1: Inventaryzacja i normalizacja. Wszystkie dokumenty źródłowe zostały zindeksowane i znormalizowane do wspólnego formatu. Każdy element (wymaganie, decyzja architektoniczna, opis komponentu) otrzymał unikalny identyfikator źródłowy (source ID) umożliwiający śledzenie pochodzenia do dokumentu źródłowego. Elementy zostały sklasyfikowane w jednej z kategorii: architektura, bezpieczeństwo, operacje, wdrożenia, biznes, produkt.

Etap 2: Identyfikacja sprzeczności. Trzy niezależne analizy bezpieczeństwa zidentyfikowały 5 krytycznych sprzeczności między dokumentami. Każda sprzeczność została udokumentowana w formacie: (a) opis sprzeczności, (b) dokumenty źródłowe, (c) analiza wpływu, (d) propozycje rozwiązania, (e) rozstrzygnięcie. Kluczowe sprzeczności dotyczyły m.in. wyboru protokołu transportowego (WireGuard vs IPsec), roli Signal w architekturze (rdzeń vs workload kompatybilnościowy) oraz zakresu rdzenia certyfikowalnego.

Etap 3: Konsolidacja. Po rozstrzygnięciu sprzeczności, materiały zostały skonsolidowane z zastosowaniem zasady: (a) nowszy dokument ma pierwszeństwo nad starszym, chyba że starszy zawiera wymaganie bezpieczeństwa nieuwzględnione w nowszym; (b) wymagania RSD mają pierwszeństwo nad dokumentacją koncepcyjną FORTRESS; (c) wnioski z analiz bezpieczeństwa mają pierwszeństwo nad wcześniejszymi założeniami architektonicznymi.

Etap 4: Walidacja kompletności. Po konsolidacji przeprowadzono analizę pokrycia (coverage analysis) weryfikującą, czy wszystkie wymagania RSD, wszystkie zidentyfikowane luki (12 otwartych gapów) oraz wszystkie scenariusze z analiz takedownów zostały zaadresowane w księdze. Elementy bez pokrycia zostały oznaczone tagiem [GAP] do uzupełnienia.

Etap 5: Tagowanie normatywności. Każdy element skonsolidowanej księgi otrzymał tag normatywności ([N], [R], [O], [E], [A]) zgodnie z kryteriami zdefiniowanymi w sekcjach 3.4–3.6.

3.3 Zasady oceny dojrzałości komponentów

Status: [N] Normatywny Odbiorca: Architekt | Dev | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 1.5, 1.7, 3.4, 3.5

Ocena dojrzałości komponentów systemu SYLION jest procesem ciągłym, realizowanym przy każdej aktualizacji księgi. Dojrzałość komponentu determinuje jego tag normatywności i wpływa na decyzje wdrożeniowe — komponent niedojrzały nie może być wdrożony w środowisku produkcyjnym, niezależnie od presji biznesowej.

Model dojrzałości SYLION (SML — SYLION Maturity Levels):

SML-0: Konceptyjny. Komponent istnieje wyłącznie jako opis wymagań lub wstępny projekt architektoniczny. Brak implementacji, brak testów. Odpowiada tagowi [E] Eksperymentalny. Przykład: niektóre scenariusze federacji Matrix z zewnętrznymi serwerami.

SML-1: Prototypowy. Istnieje działający prototyp w środowisku deweloperskim/laboratoryjnym. Przeprowadzono wstępne testy funkcjonalne. Brak testów bezpieczeństwa, brak testów wydajnościowych, brak dokumentacji operacyjnej. Odpowiada tagowi [E] Eksperymentalny. Przykład: wczesne etapy integracji PQC.

SML-2: Funkcjonalny. Komponent jest w pełni zaimplementowany i przetestowany funkcjonalnie. Przeprowadzono wstępną analizę bezpieczeństwa (threat modeling, code review). Brak pełnych testów penetracyjnych, brak doświadczenia produkcyjnego. Odpowiada tagowi [O] Opcjonalny. Przykład: Confidential Computing z AMD SEV-SNP w wariantcie bazowym.

SML-3: Produkcyjny. Komponent jest wdrożony w środowisku produkcyjnym, posiada pełną dokumentację operacyjną, przeszedł testy penetracyjne, posiada zdefiniowane procedury IR i recovery. Zebranie doświadczeń produkcyjnych (minimum 3 miesiące). Odpowiada tagowi [R] Rekomendowany lub [N] Normatywny.

SML-4: Certyfikowalny. Komponent spełnia wymagania SML-3 oraz posiada: formalne dowody bezpieczeństwa (formal verification tam gdzie stosowalne), pełną dokumentację certyfikacyjną, mapowanie na standardy (CC, FIPS, ISO), pozytywny wynik audytu niezależnego. Odpowiada wyłącznie tagowi [N] Normatywny i wchodzi w skład rdzenia certyfikowalnego.

Procedura ewaluacji: Ocena dojrzałości jest przeprowadzana przez architekta bezpieczeństwa strefy, w której operuje komponent, z udziałem zespołu QA i compliance. Wynik jest dokumentowany w formularzu ewaluacji dojrzałości i stanowi załącznik do changelog książki.

3.4 Kryteria włączania funkcji do baseline

Status: [N] Normatywny Odbiorca: Architekt | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 1.6, 1.7, 3.3, 3.5, 3.6

Włączenie funkcji lub komponentu do baseline produkcyjnego (tag [N] Normatywny) jest decyzją architektoniczną o najwyższej wadze, ponieważ oznacza, że każde wdrożenie produkcyjne SYLION musi ten element zawierać. Kryteria włączania są zatem rygorystyczne i wielowymiarowe.

Kryterium 1: Dojrzałość (SML $\geq$ 3). Komponent musi osiągnąć co najmniej poziom SML-3 (Produkcyjny) w modelu dojrzałości SYLION. Komponenty na poziomie SML-0, SML-1 lub SML-2 nie mogą wejść do baseline niezależnie od ich znaczenia architektonicznego. Wyjątek: w sytuacji, gdy brak komponentu w baseline tworzy krytyczną lukę bezpieczeństwa, Komitet Bezpieczeństwa może podjąć decyzję o włączeniu komponentu SML-2 z warunkiem osiągnięcia SML-3 w zdefiniowanym terminie (nie dłuższym niż 90 dni).

Kryterium 2: Adresowanie zidentyfikowanego zagrożenia. Komponent musi adresować co najmniej jedno zagrożenie zidentyfikowane w modelu zagrożeń SYLION. Funkcje, które nie mają uzasadnienia w modelu zagrożeń, nie wchodzą do baseline — mogą być oznaczone jako [R] lub [O]. Powiązanie komponent → zagrożenie musi być udokumentowane i weryfikowalne.

Kryterium 3: Testowalność i audytowalność. Każde wymaganie baseline musi posiadać zdefiniowany test akceptacyjny (automatyczny lub manualny) oraz zdefiniowaną procedurę audytową. Wymaganie, którego spełnienia nie można zweryfikować, nie spełnia kryterium włączenia do baseline.

Kryterium 4: Uniwersalność. Komponent baseline musi być implementowalny we wszystkich wspieranych środowiskach wdrożeniowych (cloud, hybrid, on-premises) i na wszystkich tierach. Komponent specyficzny dla jednego tieru lub jednej konfiguracji nie należy do baseline — powinien być oznaczony tagiem [R] lub [O] z adnotacją kontekstową.

Kryterium 5: Brak sprzeczności z istniejącym baseline. Nowy komponent nie może naruszać właściwości bezpieczeństwa (security properties) istniejących elementów baseline. Analiza wpływu (impact analysis) musi wykazać brak negatywnych interakcji.

Kryterium 6: Dokumentacja. Komponent musi posiadać kompletną dokumentację w księdze: opis architektoniczny, wymagania bezpieczeństwa, procedury operacyjne, procedury awaryjne i scenariusze testowe.

3.5 Kryteria oznaczania elementów jako eksperymentalne

Status: [N] Normatywny Odbiorca: Architekt | Dev | Compliance Wpływ na baseline: Średni Powiązane rozdziały: 1.7, 3.3, 3.4, 3.6

Tag [E] Eksperymentalny chroni ekosystem produkcyjny przed przedwczesnym wdrożeniem niedojrzałych komponentów, jednocześnie zapewniając przestrzeń dla innowacji i ewaluacji nowych technologii. Kryteria klasyfikacji elementu jako eksperymentalnego są komplementarne do kryteriów baseline — element, który nie spełnia kryteriów baseline, automatycznie podlega ewaluacji pod kątem klasyfikacji [E].

Pozytywne kryteria klasyfikacji [E] (wystarczy spełnienie jednego):

Dojrzałość SML-0 lub SML-1. Komponent istnieje wyłącznie jako koncepcja lub prototyp laboratoryjny. Brak walidacji produkcyjnej.

Zależność od technologii niestabilnej. Komponent zależy od technologii, standardu lub protokołu, który nie osiągnął stabilności (np. wczesne drafty specyfikacji PQC przed finalizacją NIST, eksperymentalne API Firecracker).

Brak pełnego modelu zagrożeń. Nie przeprowadzono pełnej analizy zagrożeń dla komponentu. Potencjalne wektory ataku nie są w pełni zidentyfikowane.

Ograniczone środowisko testowe. Komponent przetestowano wyłącznie w warunkach laboratoryjnych, bez symulacji obciążenia produkcyjnego, scenariuszy awarii i testów penetracyjnych.

Konflikt architektoniczny. Komponent wymaga zmian w baseline, które nie zostały jeszcze zatwierdzone. Jego wdrożenie w obecnej architekturze mogłoby naruszyć istniejące security properties.

Ograniczenia dla elementów [E]:

Elementy eksperymentalne nie mogą być wdrażane w środowiskach produkcyjnych ani w środowiskach staging powiązanych z danymi produkcyjnymi. Muszą być izolowane w dedykowanym środowisku R&D, które nie posiada łączności sieciowej ze środowiskami produkcyjnymi. Dane testowe dla komponentów [E] muszą być syntetyczne — użycie danych produkcyjnych wymaga anonimizacji i zatwierdzenia przez compliance.

Ścieżka promocji: Element [E] może zostać promowany do [O] po spełnieniu kryteriów SML-2, do [R] po spełnieniu SML-3, i do [N] po spełnieniu pełnych kryteriów baseline (sekcja 3.4). Każda promocja wymaga formalnej ewaluacji i zatwierdzenia przez Architekta Głównego.

Rejestr eksperymentalny: Wszystkie elementy [E] muszą być zarejestrowane w Rejestrze Eksperymentalnym zawierającym: opis komponentu, cel eksperymentu, oczekiwany termin ewaluacji, właściciela, zidentyfikowane ryzyka oraz kryteria sukcesu/porażki. Rejestr jest przeglądany kwartalnie.

3.6 Zasady rozdziału rdzenia certyfikowalnego od modułów autonomicznych

Status: [N] Normatywny Odbiorca: Architekt | Compliance | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 1.7, 3.4, 3.5, 4.3

Jedną z kluczowych innowacji architektonicznych SYLION 3.0 w stosunku do poprzednika FORTRESS jest formalne rozdzielanie rdzenia certyfikowalnego (certifiable core) od modułów autonomicznych (autonomous modules). Rozdzielenie to adresuje fundamentalny problem platform bezpieczeństwa: jak zachować rygorystyczne gwarancje bezpieczeństwa rdzenia przy jednoczesnym zapewnieniu elastyczności operacyjnej i możliwości adaptacji do specyficznych potrzeb operatorów.

Rdzeń certyfikowalny obejmuje komponenty, których poprawne działanie jest warunkiem koniecznym dla właściwości bezpieczeństwa całego systemu. Są to elementy oznaczone tagiem [N] Normatywny, które podlegają: - Formalnemu procesowi zarządzania zmianą (change management) z zatwierdzeniem Komitetu Bezpieczeństwa. - Testom regresji bezpieczeństwa przy każdej modyfikacji. - Audytowi niezależnemu (co najmniej raz w roku lub po istotnej zmianie). - Certyfikacji według stosownych standardów (CC, FIPS, ISO — w zależności od tieru). - Dokumentacji formal-verification tam, gdzie jest to wykonalne.

Do rdzenia certyfikowalnego należą m.in.: model stref bezpieczeństwa (0–5), Split Gateway (G1/G2), stos kryptograficzny (HSM/PKI/PQC), protokół transportowy (IPsec IKEv2), mechanizm izolacji workloadów (Firecracker microVM), mechanizm immutability infrastruktury oraz polityki Zero Trust.

Moduły autonomiczne [A] to komponenty, których konfiguracja i zarządzanie są delegowane operatorowi w ramach zdefiniowanych guardrails. Operator może je dostosowywać do swoich potrzeb bez wpływu na rdzeń certyfikowalny. Do modułów autonomicznych należą m.in.: polityki retencji danych (w ramach dozwolonych zakresów), konfiguracja integracji z systemami klienta (SSO, SIEM), parametryzacja powiadomień i alertingu, zarządzanie użytkownikami w ramach swojej organizacji, konfiguracja kanałów komunikacyjnych Matrix.

Zasada granicy: Moduł autonomiczny nie może modyfikować zachowania rdzenia certyfikowalnego. Interfejs między rdzeniem a modułami autonomicznymi musi być zdefiniowany jako API z walidacją wejść — rdzeń odrzuca każde żądanie z modułu autonomicznego, które naruszałoby jego security properties. Granica ta musi być egzekwowana technicznie (nie wyłącznie proceduralnie).

3.7 Metoda opisu ryzyk rezydualnych

Status: [N] Normatywny Odbiorca: Architekt | SOC | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 3.4, 3.8, 3.9

Żaden system bezpieczeństwa nie eliminuje wszystkich ryzyk. Uczciwe i systematyczne dokumentowanie ryzyk rezydualnych — czyli ryzyk, które pozostają po wdrożeniu wszystkich mechanizmów ochronnych — jest warunkiem wiarygodności dokumentu i wymogiem regulacyjnym. Próba ukrycia ryzyk rezydualnych podważa zaufanie do platformy i jest sprzeczna z filozofią SYLION.

Format opisu ryzyka rezydualnego:

Każde ryzyko rezydualne w księdze musi być opisane w ustandaryzowanym formacie:

> **ID ryzyka:** RR-XXX > **Strefa:** [0–5] > **Klasa adversarza:** [Oportunistyczny | Zaawansowany | Państwowy | Supply-chain] > **Opis:** [Zwięzły opis ryzyka] > **Mechanizmy mitigacji:** [Wdrożone mechanizmy ograniczające ryzyko] > **Ryzyko rezydualne:** [Co pozostaje po mitigacji] > **Wpływ:** [Krytyczny | Wysoki | Średni | Niski] > **Prawdopodobieństwo:** [Wysokie | Średnie | Niskie | Bardzo niskie] > **Akceptacja:** [Zaakceptowane przez: rola/data | Niezaakceptowane — wymaga działania] > **Plan remediacji:** [Jeśli niezaakceptowane — opis planu i termin]

Zasada kompletności: Każdy rozdział opisujący mechanizm bezpieczeństwa musi kończyć się sekcją „Ryzyka rezydualne”, identyfikującą ryzyka, których dany mechanizm nie eliminuje. Brak sekcji ryzyk rezydualnych jest traktowany jako niezgodność z metodyką księgi.

Zasada jawności: Ryzyka rezydualne nie są ukrywane przed odbiorcami — są dostępne na odpowiednim poziomie szczegółowości. Klienci enterprise otrzymują podsumowanie ryzyk rezydualnych odpowiednie do ich tieru. Audytorzy otrzymują pełną listę. Zarząd otrzymuje kwartalny raport z priorytetyzacją.

Zasada aktualizacji: Rejestr ryzyk rezydualnych musi być przeglądany co kwartał. Nowe ryzyka mogą pojawić się w wyniku: zmiany krajobrazu zagrożeń, nowych publikacji o podatnościach, wniosków z incydentów, zmian regulacyjnych lub modyfikacji architektury. Każdy przegląd musi być udokumentowany.

Zasada eskalacji: Ryzyko rezydualne o wpływie Krytycznym i prawdopodobieństwie wyższym niż Niskie musi być eskalowane do Komitetu Bezpieczeństwa i zarządu. Brak akceptacji takiego ryzyka blokuje wdrożenie na tierze, którego dotyczy.

3.8 Metoda opisu scenariuszy ataku i obrony

Status: [N] Normatywny Odbiorca: Architekt | SOC | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 3.1, 3.7, 3.9

Scenariusze ataku i obrony stanowią operacyjną warstwę modelu zagrożeń. O ile model zagrożeń definiuje „kto może atakować i dlaczego”, scenariusze opisują „jak konkretnie atak przebiega i jak system się broni”. Metoda opisu scenariuszy w księdze jest bezpośrednio inspirowana analizą rzeczywistych takedownów platform encrypted (EncroChat, Sky ECC, ANOM, Ghost, MATRIX), które dostarczyły empirycznych danych o taktykach, technikach i procedurach (TTP) stosowanych przez agencje ścigania i służby wywiadowcze.

Format opisu scenariusza:

> **ID scenariusza:** SA-XXX > **Nazwa:** [Opisowa nazwa scenariusza] > **Klasa adversarza:** [Oportunistyczny | Zaawansowany | Państwowy | Supply-chain] > **Wektor ataku:** [Opis wektora] > **Strefa wejścia:** [0–5] > **Cel ataku:** [Poufność | Integralność | Dostępność | Autentyczność] > **Kill chain:** [Opis kroków ataku — reconnaissance → weaponization → delivery → exploitation → installation → C2 → actions on objective] > **Mechanizmy obrony (per krok):** [Dla każdego kroku kill chain — jakie mechanizmy SYLION blokują lub wykrywają] > **Punkt detekcji:** [W którym kroku SOC powinien wykryć atak] > **Punkt blokady:** [W którym kroku atak jest automatycznie blokowany] > **Ryzyko rezydualne:** [Referencja do RR-XXX] > **Referencja empiryczna:** [Jeśli scenariusz jest inspirowany rzeczywistym incydentem — referencja]

Kategorie scenariuszy:

Scenariusze są podzielone na kategorie odpowiadające klasom adversary:

Scenariusze oportunistyczne — ransomware, phishing, credential stuffing, exploitation znanych CVE. Adresowane głównie przez baseline [N].

Scenariusze zaawansowane — APT z custom toolingiem, lateral movement, persistence. Adresowane przez [N] + [R].

Scenariusze państwowe — ataki z zasobami państwowymi, exploits 0-day, kompromitacja supply chain, insider threat z dostępem fizycznym. Adresowane przez pełny zakres STATE/SOVEREIGN.

Scenariusze supply-chain — kompromitacja dostawcy komponentów, manipulacja aktualizacjami, backdoor w zależnościach. Adresowane przez politykę immutable infrastructure i weryfikację integralności.

Zasada empiryzmu: Scenariusze nie są teoretyczne — każdy scenariusz musi być uzasadniony albo rzeczywistym incydem (np. takedown EncroChat, w którym agencja uzyskała dostęp do serwerów i wdrożyła aktualizację z backdoorem), albo udokumentowaną techniką z MITRE ATT&CK, albo wynikiem testu penetracyjnego. Scenariusze czysto hipotetyczne są dopuszczalne wyłącznie dla klasy adversary „supply-chain” i muszą być oznaczone tagiem [HYPOTHETICAL].

3.9 Metoda opisu decyzji architektonicznych

Status: [N] Normatywny Odbiorca: Architekt | Dev | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 1.2, 1.9, 3.1, 3.2, 4.3

Każda istotna decyzja architektoniczna opisana w księdze musi być udokumentowana w sposób umożliwiający zrozumienie nie tylko „co” zostało zdecydowane, ale „dlaczego”, „jakie alternatywy rozważano” i „jakie kompromisy zaakceptowano”. Metoda ta jest krytyczna dla utrzymania spójności systemu w czasie — nowi członkowie zespołu muszą rozumieć kontekst decyzji, aby nie podejmować zmian podważających ich racjonalne.

Format opisu decyzji architektonicznej (ADR w księdze):

```
> **ID decyzji:** AD-XXX > **Data:** [YYYY-MM-DD] > **Status:** [Zatwierdzona | W dyskusji | Zastąpiona przez AD-YYY] > **Kontekst:** [Opis problemu lub potrzeby, która wywołała decyzję] > **Rozważane warianty:** > - Wariant A: [opis, zalety, wady] > - Wariant B: [opis, zalety, wady] > - Wariant C: [opis, zalety, wady] > **Decyzja:** [Wybrany wariant i uzasadnienie] > **Konsekwencje:** [Pozytywne i negatywne skutki decyzji] > **Kompromisy:** [Jakie właściwości poświęcono i dlaczego] > **Zatwierdzenie:** [Kto zatwierdził i kiedy]
```

Kluczowe decyzje architektoniczne SYLION 3.0 dokumentowane tą metodą:

AD-001: WireGuard → IPsec IKEv2 — decyzja o rezygnacji z WireGuard na rzecz IPsec IKEv2 ze względu na zgodność z FIPS 140-3 i CNSA 2.0. Warianty: (a) zachowanie WireGuard z wrapperem FIPS, (b) WireGuard + IPsec dual-stack, (c) pełna migracja na IPsec. Wybrano wariant (c) — uzasadnienie: uproszczenie stosu, zgodność certyfikacyjna, eliminacja ryzyka audytowego.

AD-002: Signal → Matrix — decyzja o degradacji Signal do roli workloadu kompatybilnościowego i promowaniu Matrix jako rdzenia komunikacyjnego. Motywacja: kontrola nad protokołem, możliwość federacji, otwartość standardu, eliminacja zależności od infrastruktury Signal Foundation.

AD-003: Wprowadzenie rdzenia certyfikowalnego vs modułów autonomicznych — formalizacja rozdzielenia zainspirowana analizą incydentów z platformami EncroChat, Sky ECC i ANOM, gdzie brak wyraźnej granicy między rdzeniem a konfigurowalnymi modułami ułatwiał kompromitację.

Zasada niezmienności decyzji: Zatwierdzona decyzja architektoniczna nie może zostać zmieniona bez formalnego procesu. Zmiana wymaga: nowego ADR (ze statusem „Zastępuje AD-XXX”), analizy wpływu na baseline, zatwierdzenia Architekta Głównego i aktualizacji wszystkich powiązanych sekcji księgi.

3.10 Zasady aktualizacji księgi

Status: [N] Normatywny Odbiorca: Architekt | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 1.5, 1.8, 4.1–4.8

Księga Systemu jest dokumentem żywym — podlega regularnym aktualizacjom wynikającym ze zmian architektonicznych, nowych wymagań regulacyjnych, wniosków z incydentów, postępu na roadmapie oraz zmian w krajobrazie zagrożeń. Proces aktualizacji musi być sformalizowany, aby zapewnić spójność dokumentu i identyfikowalność zmian.

Cykl aktualizacji:

Aktualizacje kwartalne (planowe) — przegląd całego dokumentu, aktualizacja statusów dojrzałości komponentów, przegląd rejestru ryzyk rezydualnych, synchronizacja z roadmapą produktu. Wynikiem jest wersja pomocnicza (minor version, np. 3.1.0 → 3.2.0).

Aktualizacje reaktywne (ad-hoc) — wywołane przez: krytyczną zmianę architektoniczną, incydent bezpieczeństwa wymagający korekty modelu zagrożeń, nowe wymagania regulacyjne z krótkim terminem lub wykrycie krytycznej niespójności w dokumencie. Wynikiem jest wersja redakcyjna (patch version, np. 3.2.0 → 3.2.1) lub wersja pomocnicza w przypadku istotnych zmian.

Aktualizacje główne (major version) — wywołane przez fundamentalne zmiany w architekturze systemu (np. przejście z FORTRESS na SYLION, przejście na SYLION 3.0). Wymagają pełnego cyklu przeglądu i zatwierdzenia.

Proces aktualizacji:

Krok 1: Propozycja zmiany — złożenie Change Request (CR) z opisem zmiany, uzasadnieniem i analizą wpływu na istniejące rozdziały.

Krok 2: Recenzja — przegląd CR przez właściciela rozdziału, architekta bezpieczeństwa i zespół compliance. Dla zmian wpływających na baseline — recenzja przez Architekta Głównego.

Krok 3: Implementacja — wprowadzenie zmiany do dokumentu z aktualizacją metadanych (status, powiązane rozdziały) i rejestru zmian (changelog).

Krok 4: Walidacja — weryfikacja spójności zmiany z pozostałymi rozdziałami. Automatyczne sprawdzenie referencji krzyżowych (jeśli narzędzia dostępne).

Krok 5: Publikacja — opublikowanie nowej wersji zgodnie z polityką publikacji (patrz Rozdział 4.8) i powiadomienie listy dystrybucyjnej.

Zamrożenie dokumentu: W okresie audytu zewnętrznego lub certyfikacji, księga podlega zamrożeniu (document freeze) — żadne zmiany nie mogą być wprowadzane bez zatwierdzenia Komitetu Bezpieczeństwa. Okres zamrożenia musi być ogłoszony z co najmniej 14-dniowym wyprzedzeniem.

Rozdział 4. Historia wersji i polityka wersjonowania

4.1 Konwencja wersji dokumentu

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance Wpływ na baseline: Średni Powiązane rozdziały: 1.5, 4.2, 4.3, 4.5

Księga Systemu SYLION stosuje konwencję wersjonowania semantycznego (Semantic Versioning) dostosowaną do specyfiki dokumentacji architektonicznej. Konwencja ta zapewnia, że numer wersji jednoznacznie komunikuje charakter i zakres zmian, umożliwiając odbiorcom szybką ocenę, czy nowa wersja wymaga ich uwagi.

Format numeru wersji: MAJOR.MINOR.PATCH[-qualifier]

MAJOR (wersja główna) — inkrementowana przy fundamentalnych zmianach w architekturze systemu lub modelu bezpieczeństwa. Zmiana wersji głównej oznacza, że poprzednia wersja jest niekompatybilna z nową — wymagania mogły zostać usunięte, zmienione lub dodane w sposób wymagający pełnego przeglądu wdrożeń. Przykład: przejście z SYLION 2.x na SYLION 3.0 (wprowadzenie rdzenia certyfikowalnego, zmiana IPsec, Matrix jako rdzeń).

MINOR (wersja pomocnicza) — inkrementowana przy dodaniu nowych rozdziałów, istotnych zmianach w istniejących rozdziałach (modyfikacja wymagań [N] lub [R]), dodaniu nowych komponentów do baseline lub zmianach w modelu zagrożeń. Kompatybilna wstecz — istniejące wymagania pozostają ważne, dodawane są nowe.

PATCH (wersja redakcyjna) — inkrementowana przy korektach edytorskich, uściśleniach interpretacyjnych, poprawkach referencji krzyżowych, aktualizacjach metadanych rozdziałów. Nie zmienia wymagań merytorycznych.

Qualifier (kwalifikator) — opcjonalny sufix: -draft (wersja robocza), -rc1 (release candidate), -review (w trakcie przeglądu). Brak kwalifikatora oznacza wersję zatwierdzoną (APPROVED).

Przykłady: - 3.0.0-draft — pierwsza wersja robocza SYLION 3.0 - 3.0.0-rc1 — kandydat do wydania, po przeglądzie - 3.0.0 — wersja zatwierdzona, produkcyjna - 3.1.0 — pierwsza aktualizacja kwartalna - 3.1.1 — korekta redakcyjna

Zasada monotoniczności: Numery wersji mogą wyłącznie rosnąć. Wersja nigdy nie jest wycofywana — w przypadku wykrycia błędu, publikowana jest nowa wersja z wyższym numerem i opisem korekty w changelog.

4.2 Wersjonowanie główne, pomocnicze i redakcyjne

Status: [N] Normatywny Odbiorca: Architekt | Compliance Wpływ na baseline: Średni Powiązane rozdziały: 4.1, 4.3, 4.5, 4.6

Niniejsza sekcja szczegółowo definiuje zasady kwalifikacji zmian do poszczególnych poziomów wersjonowania. Precyzyjna kwalifikacja jest istotna, ponieważ każdy poziom wersji implikuje inny proces zatwierdzania, inny zakres recenzji i inne wymagania powiadamiania.

Zmiany kwalifikujące się jako MAJOR (wersja główna):

Fundamentalna zmiana modelu architektonicznego (np. zmiana topologii stref, zmiana modelu izolacji, zmiana rdzenia komunikacyjnego).

Zmiana protokołu transportowego lub stosu kryptograficznego w sposób niekompatybilny wstecz.

Usunięcie lub istotna modyfikacja wymagania [N] baseline, która wymaga zmian wdrożeniowych u wszystkich operatorów.

Wprowadzenie nowego tieru produktowego lub usunięcie istniejącego.

Zmiana modelu zagrożeń na poziomie strategicznym (nowa klasa adwersarza, redefinicja granic zaufania).

Zatwierdzenie: Komitet Bezpieczeństwa + Zarząd. Recenzja: pełna (wszyscy właściciele rozdziałów). Powiadomienie: wszyscy odbiorcy, partnerzy, klienci affected.

Zmiany kwalifikujące się jako MINOR (wersja pomocnicza):

Dodanie nowego rozdziału lub podrozdziału.

Dodanie nowego komponentu do baseline [N] (o ile nie zmienia fundamentalnie architektury).

Modyfikacja wymagania [R] lub [O] (promowanie, degradowanie, zmiana treści).

Aktualizacja modelu zagrożeń na poziomie taktycznym (nowe scenariusze, aktualizacja TTP).

Dodanie nowych ryzyk rezydualnych lub zmiana oceny istniejących.

Aktualizacja matryc mapowania na standardy.

Zatwierdzenie: Architekt Główny + właściciel(-e) zmienionych rozdziałów. Recenzja: targetowana (właściciele powiązanych rozdziałów). Powiadomienie: zespoły affected + compliance.

Zmiany kwalifikujące się jako PATCH (wersja redakcyjna):

Korekty ortograficzne, gramatyczne, stylistyczne.

Uściślenia interpretacyjne niemodyfikujące wymagań.

Poprawki referencji krzyżowych i metadanych.

Aktualizacja statusu dojrzałości komponentu (bez zmiany tagu normatywności).

Dodanie przykładów lub wyjaśnień do istniejących wymagań.

Zatwierdzenie: Właściciel rozdziału. Recenzja: minimalna (self-review + peer review). Powiadomienie: opcjonalne.

4.3 Historia ewolucji: FORTRESS → SYLION → SYLION 3.0

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 3.1, 3.2, 3.9, 4.1

Zrozumienie historii ewolucji platformy jest niezbędne do prawidłowej interpretacji decyzji architektonicznych SYLION 3.0. Wiele wyborów projektowych jest bezpośrednią konsekwencją lekcji wyciągniętych z poprzednich iteracji i analizy incydentów w branży.

Faza 1: FORTRESS (koncepcja pierwotna)

Platforma FORTRESS stanowiła oryginalną wizję bezpiecznego systemu komunikacji i pracy zdalnej. Kluczowe cechy: - WireGuard jako protokół transportowy — wybrany ze względu na prostotę, wydajność i nowoczesność kodu. - Signal jako rdzeń komunikacyjny — wybrany ze względu na uznaną reputację protokołu Signal (Double Ratchet, X3DH). - Architektura bezpieczna, lecz mniej formalnie ustrukturyzowana — brak wyraźnego rozdzielenia rdzenia certyfikowalnego od modułów autonomicznych. - Wstępny model stref i izolacji — koncepcja segmentacji istniała, lecz nie została sformalizowana w model sześciu stref.

FORTRESS stanowił solidny punkt wyjścia, lecz analiza krajobrazu zagrożeń ujawniła fundamentalne ograniczenia.

Punkt zwrotny: analiza takedownów platform encrypted

Systematyczna analiza operacji rozbijania platform szyfrowanej komunikacji (EncroChat — 2020, Sky ECC — 2021, ANOM — 2018–2021, Ghost — 2024, MATRIX — 2024) dostarczyła empirycznych danych o taktach stosowanych przez agencje ścigania i służby wywiadowcze. Kluczowe wnioski:

EncroChat: agencje uzyskały dostęp do serwerów i wdrożyły złośliwą aktualizację OTA — lekcja: infrastruktura immutable z weryfikacją integralności aktualizacji jest krytyczna.

Sky ECC: kompromitacja poprzez przejęcie infrastruktury serwerowej — lekcja: model Thin Client z Confidential Computing chroni dane nawet przy kompromitacji hosta.

ANOM: platforma od początku kontrolowana przez FBI — lekcja: transparentność architektury i audytowalność eliminują ryzyko wbudowanego backdoora.

Ghost: kompromitacja poprzez modyfikację firmware urządzeń — lekcja: atestacja sprzętowa i Confidential Computing.

MATRIX: infiltracja poprzez przejęcie zaproszenia i kompromitację serwera — lekcja: architektura Zero Trust z mikrosegmentacją, gdzie kompromitacja jednego elementu nie daje dostępu do całości.

Faza 2: SYLION v1/v2 (iteracyjna ewolucja)

Na podstawie wniosków z analizy FORTRESS i takedownów, rozpoczęto prace nad platformą SYLION, wprowadzając: model Split Gateway (G1/G2), formalizację stref bezpieczeństwa, mikrosegmentację per-operator oraz infrastrukturę immutable.

Punkt zwrotny: trzy niezależne analizy bezpieczeństwa

Trzy niezależne analizy bezpieczeństwa (analiza Claude, analiza Gemini, dokument łatania podatności) przeprowadzone na dokumentacji SYLION v2 ujawniły: - 5 krytycznych sprzeczności: (1) niespójność między deklarowanym Zero Trust a faktycznym zaufaniem do WireGuard w kontekście certyfikacyjnym; (2) rola Signal jako rdzenia przy jednoczesnej deklaracji niezależności od infrastruktury stron trzecich; (3) brak formalnej granicy między rdzeniem certyfikowalnym a elementami konfiguracyjnymi; (4) niespójność wymagań kryptograficznych między strefami; (5) brak formalnego modelu zagrożeń z klasami adversarzy. - 12 otwartych luk: obejmujących m.in. brak specyfikacji CDR, niedostateczną definicję procedur IR w architekturze immutable, brak polityki PQC, niedostateczną definicję granic autonomii operatora.

Faza 3: SYLION 3.0 (obecna wersja)

SYLION 3.0 stanowi odpowiedź na wszystkie zidentyfikowane problemy. Kluczowe zmiany w stosunku do poprzedników:

WireGuard → IPsec IKEv2 — migracja protokołu transportowego dla pełnej zgodności z FIPS 140-3 i CNSA 2.0. Eliminacja ryzyka audytowego związanego z brakiem certyfikacji FIPS dla WireGuard.

Signal → Matrix — degradacja Signal do roli workloadu kompatybilnościowego (utrzymywanego dla użytkowników migrujących) i promocja Matrix jako rdzenia komunikacyjnego z pełną kontrolą nad protokołem i możliwością federacji.

Formalne rozdzielenie rdzenia certyfikowalnego od modułów autonomicznych — jasna granica techniczna i proceduralna.

Wprowadzenie stosu HSM/PKI/PQC — pełna hierarchia kryptograficzna z HSM jako root of trust, PKI do zarządzania certyfikatami i przygotowaniem do kryptografii postquantumowej.

Formalny model zagrożeń z klasami adversarzy — od oportunistycznych po państwowe i supply-chain, z empirycznym uzasadnieniem opartym na analizie takedownów.

Identyfikacja Hypori jako najbliższego analogu komercyjnego — model VMI-based, FedRAMP High, DoD IL5 jako benchmark dla pozycjonowania SYLION, szczególnie w segmencie STATE/SOVEREIGN.

4.3.1 ADR-001: Zmiana protokołu transportowego WireGuard → IPsec IKEv2

Status: ZATWIERDZONE | Data decyzji: 2026-03-15 | Właściciel: Architekt Główny | Identyfikator: ADR-001 | Wpływ: KRYTYCZNY — zmiana fundamentalna (MAJOR w semantic versioning)

Kontekst: Platforma FORTRESS/SYLION pierwotnie używała WireGuard jako protokołu VPN ze względu na jego prostotę, wydajność i nowoczesny design kryptograficzny (Curve25519, ChaCha20-Poly1305). W trakcie analizy rynku docelowego (klienci rządowi, sektor obronny, regulowane sektory finansowe) zidentyfikowano fundamentalną barierę: WireGuard nie posiada żadnej z kluczowych certyfikacji wymaganych przez te segmenty.

Zidentyfikowany problem: WireGuard nie posiada certyfikacji FIPS 140-3 (wymagany przez US Federal). Brak na liście CSfC (Commercial Solutions for Classified — NSA). Brak zgodności z DISA STIG (wymagany dla deploymentów DoD). Brak wsparcia NIAP Common Criteria. Niezgodność z CNSA 2.0 (wymaga wsparcia PQC w IPsec do 2026, wyłączość IPsec do 2030). Brak natywnej integracji X.509/PKI. Brak mechanizmu per-connection certificate validation.

Rozważane alternatywy: (A) WireGuard + hybrydowy PQC przez PSK (ML-KEM za pomocą pre-shared key). Zalety: minimalna zmiana, +15-20ms latencji. Wady: nadal brak FIPS/CSfC/STIG — problem certyfikacyjny pozostaje nierozwiązany. (B) IPsec IKEv2 z strongSwan 6.0.0. Zalety: pełna ścieżka certyfikacyjna FIPS/CSfC/DISA STIG/NIAP CC, natywne PKI/X.509, ML-KEM przez RFC 9370 (Multiple Key Exchanges), CNSA 2.0 compliance, IKE MOBIKE dla seamless reconnect. Wady: większa złożoność konfiguracji, wyższy próg wejścia dla operatorów. (C) OpenVPN. Zdyskwalifikowany: przestarzały, brak PQC, niższa wydajność.

Decyzja: Wybrano opcję (B) — IPsec IKEv2 z strongSwan 6.0.0. Uzasadnienie biznesowe: Hypori (jedyne bezpośredni konkurent) uzyskał FedRAMP High w marcu 2025 przy użyciu IPsec. Bez ekwiwalentnej certyfikacji rynek rządowy jest de facto zamknięty. Uzasadnienie techniczne: strongSwan 6.0.0 (grudzień 2024) jako pierwszy implementuje ML-KEM-1024 przez RFC 9370. Konfiguracja referencyjna CNSA 2.0: aes256gcm16-prfsha384-ecp384-ke1_mlkem1024. Uwaga dotycząca przepustowości: IPsec IKEv2 wykazuje ~15% niższą przepustowość w porównaniu do WireGuard w benchmarkach (overhead protokołu i dodatkowe negocjacje IKE). Jest to świadomy kompromis na rzecz certyfikowalności — przy typowych sesjach SYLION (sesja pikselowa + audio) różnica jest nieistotna operacyjnie.

Ryzyka i mitigacje: Ryzyko złożoności operacyjnej — mitigacja: IaC (Terraform/Ansible) abstrakcja konfiguracji strongSwan, centralny management plane. Ryzyko NAT traversal (Starlink CGNAT) — mitigacja: UDP 4500 NAT-T obowiązkowy, IKE MOBIKE dla IP mobility. Ryzyko latencji IKE handshake — mitigacja: IKEv2 Session Resumption (RFC 5723), cache SA.

Konsekwencje dla dokumentacji: Wszystkie dokumenty (RSD, FULL, materiały marketingowe) muszą spójnie opisywać IPsec IKEv2 jako jedyny protokół transportowy rdzenia certyfikowalnego. WireGuard może być opisywany wyłącznie w kontekście historycznym lub jako odrzucona alternatywa.

4.3.2 Macierz zmian FORTRESS → SYLION 3.0

Element	FORTRESS	SYLION 3.0	Status
VPN transport	WireGuard	IPsec IKEv2 + strongSwan 6.0	[N] Zmiana obligatoryjna (ADR-001)
Komunikator rdzeń	Signal (główny)	Matrix / własny homeserver	[N] Zmiana strategiczna
Signal	Główny komunikator	Izolowany workload [env-signal] w microVM	[R] Zdegradowany
G1 Network Gateway	Zachowany	Zachowany — terminacja IPsec, ACL, rate limiting	[N] Bez zmian
G2 Access Broker	Zachowany	Per-session guacd izolacja, CDR pipeline	[N] Wzmocniony
MicroVM Firecracker	Opcjonalny	Obowiązkowy dla env-signal, env-voice, high-risk	[N] Wzmocniony
Confidential Computing	Rekomendowany	AMD SEV-SNP / Intel TDX z atestacją przed sekretem	[R] Sformalizowany
PQC	STATE-LEVEL	ML-KEM-1024 przez RFC 9370, ścieżka CNSA 2.0	[R] Wzmocniony
HSM	Opcjonalny	Obowiązkowy PRO+ dla kluczy CA i transportowych	[N] Wzmocniony
Rotacja IMSI/IMEI	Wbudowana	Moduł autonomiczny [A] — poza rdzeniem certyfikowalnym	[A] Przeniesiony
Dead Man Switch	Opcjonalny	Aktywny PRO (72h), konfigurowalny STATE	[N] Sformalizowany
Streaming	RDP/VNC standard	Model A [N] per-session TEE + Model B [E] SFrame AV	[E] Rozbudowany
Dark-Matrix (.onion)	STATE-LEVEL	Matrix Synapse jako Tor Hidden Service + UnifiedPush	[R] Sformalizowany

4.4 Zasady utrzymania zmian

Ograniczenie platformowe: iOS i push notifications. UnifiedPush (self-hosted ntfy) działa wyłącznie na Android. Apple iOS wymaga Apple Push Notification Service (APNs), co oznacza, że metadane push (timestamp, device token) przechodzą przez serwery Apple. Konsekwencje dla operatorów SYLION korzystających z iPhone jako terminala desktopowego: (a) komunikacja Matrix działa normalnie (E2EE zachowane), (b) powiadomienia push ujawniają Apple fakt otrzymania wiadomości (nie treść), (c) alternatywa: tryb polling (sprawdzanie co 15-30 sekund) eliminuje metadane do Apple, ale zwiększa zużycie baterii i wprowadza opóźnienia powiadomień. Rekomendacja: Pixel z GrapheneOS jako terminal referencyjny eliminuje ten problem. iPhone jako terminal desktopowy: dopuszczalny z udokumentowaną akceptacją ryzyka metadata leakage do Apple. To ograniczenie wynika z polityki Apple i nie może zostać rozwiązane po stronie SYLION.

Status: [N] Normatywny Odbiorca: Architekt | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 3.10, 4.1, 4.2, 4.5, 4.6

Zarządzanie zmianami w Księdze Systemu podlega ścisłemu procesowi, którego celem jest zapewnienie: integralności dokumentu, identyfikowalności modyfikacji, kontroli jakości i właściwego powiadamiania interesariuszy. Proces ten jest niezależny od zarządzania zmianami w kodzie platformy, choć obie ścieżki muszą być zsynchronizowane.

Change Request (CR) — format:

Każda propozycja zmiany w księdze musi zostać złożona jako formalny Change Request zawierający:

Identyfikator CR: CR-YYYY-NNN (rok + numer sekwencyjny).

Autor: imię, rola, zespół.

Typ zmiany: MAJOR / MINOR / PATCH (wstępna kwalifikacja — ostateczna kwalifikacja należy do recenzenta).

Rozdziały affected: lista rozdziałów i podrozdziałów wymagających modyfikacji.

Uzasadnienie: dlaczego zmiana jest potrzebna (nowe wymaganie, korekta błędu, reakcja na incydent, zmiana regulacyjna, wniosek z audytu).

Opis zmiany: szczegółowy opis proponowanych modyfikacji (diff format preferowany).

Analiza wpływu: ocena wpływu na: baseline, inne rozdziały, dokumentację wykonawczą, materiały szkoleniowe, wdrożenia produkcyjne.

Referencje: ADR, wyniki audytu, raporty incydentowe lub inne dokumenty uzasadniające zmianę.

Workflow zatwierdzania:

CR przechodzi przez następujące stany:

SUBMITTED — CR złożony, oczekuje na triage.

TRIAGED — CR oceniony, przypisany do recenzenta(-ów), kwalifikacja potwierdzona lub zmieniona.

IN REVIEW — CR w trakcie recenzji. Recenzent może zatwierdzić, odrzucić lub zażądać zmian.

APPROVED — CR zatwierdzony. Zmiana może być wprowadzona do dokumentu.

IMPLEMENTED — zmiana wprowadzona do dokumentu, oczekuje na walidację.

VALIDATED — zmiana zwalidowana (spójność referencji krzyżowych, metadanych, changelog).

PUBLISHED — zmiana opublikowana w nowej wersji dokumentu.

REJECTED — CR odrzucony z udokumentowanym uzasadnieniem.

Zasada nieodwracalności: Zatwierdzony i opublikowany CR nie może być „wycofany” — w przypadku wykrycia błędu, składany jest nowy CR korygujący. Historia zmian musi być kompletna i nieedytowalna.

Zasada terminowości: CR o prioryecie krytycznym (np. wynikający z incydentu bezpieczeństwa) musi być przetworzony w ciągu 5 dni roboczych. CR o prioryecie standardowym — w ciągu 20 dni roboczych. CR o prioryecie niskim — w następnym cyklu aktualizacji kwartalnej.

4.5 Rejestr zmian i change log

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner Wpływ na baseline: Średni Powiązane rozdziały: 4.1, 4.2, 4.4

Rejestr zmian (changelog) stanowi integralną część Księgi Systemu i musi być utrzymywany z każdą publikowaną wersją. Changelog jest narzędziem komunikacji — umożliwia odbiorcom szybkie zrozumienie, co się zmieniło, bez konieczności porównywania pełnych wersji dokumentu.

Format wpisu changelog:

[Wersja] — [YYYY-MM-DD] ### Dodane - [Rozdział X.Y] Opis dodanej treści. (CR-YYYY-NNN) ### Zmienione - [Rozdział X.Y] Opis zmiany. Poprzednio: [stare brzmienie]. Obecnie: [nowe brzmienie]. (CR-YYYY-NNN) ### Usunięte - [Rozdział X.Y] Opis usuniętej treści i uzasadnienie. (CR-YYYY-NNN) ### Naprawione - [Rozdział X.Y] Opis korekty (błąd, niespójność, brakująca referencja). (CR-YYYY-NNN) ### Bezpieczeństwo - [Rozdział X.Y] Zmiany wynikające z incydentów bezpieczeństwa lub aktualizacji modelu zagrożeń. (CR-YYYY-NNN) ### Statusy - [Rozdział X.Y] Zmiana statusu normatywności: [stary tag] → [nowy tag]. (CR-YYYY-NNN) - [Komponent X] Zmiana poziomu dojrzałości: SML-N → SML-M. (CR-YYYY-NNN)

Wymagania dla changelog:

Kompletność: Każda zmiana musi być odnotowana. Brak wpisu changelog dla opublikowanej zmiany stanowi niezgodność z metodyką.

Identyfikowalność: Każdy wpis musi zawierać referencję do CR, który go wywołał.

Czytelność: Wpisy muszą być zrozumiałe bez kontekstu — odbiorca powinien zrozumieć istotę zmiany z samego wpisu changelog.

Priorytetyzacja: Wpisy w kategorii „Bezpieczeństwo” muszą być wylistowane na początku, ponieważ mają najwyższy priorytet dla odbiorców.

Retencja: Changelog jest kumulatywny — zawiera wpisy dla wszystkich wersji od 3.0.0. Historia sprzed SYLION 3.0 (FORTRESS, SYLION v1/v2) jest podsumowana w sekcji 4.3.

Inicjalny changelog SYLION 3.0:

[3.0.0-draft] — 2026-04-05 ### Dodane - Pełna Część I: Fundament dokumentu, zakres i zasady interpretacji (R. 1–4). - Formalne rozdzielenie rdzenia certyfikowalnego od modułów autonomicznych. - Model dojrzałości komponentów SML (0–4). - Trójstopniowy system normatywny (musi/powinien/może). - Format opisu ryzyk rezidualnych, scenariuszy ataku i decyzji architektonicznych. ### Zmienione - Protokół transportowy: WireGuard → IPsec IKEv2 (FIPS/CNSA 2.0). - Rdzeń komunikacyjny: Signal → Matrix (Signal degradowany do workloadu kompatybilnościowego). - Model zagrożeń: wprowadzenie formalnych klas adwersarzy. ### Bezpieczeństwo - Zaadresowanie 5 krytycznych sprzeczności zidentyfikowanych w trzech niezależnych analizach. - Zaadresowanie 12 otwartych luk z analiz SYLION v2.

4.6 Zasady recenzji i zatwierdzania

Status: [N] Normatywny Odbiorca: Architekt | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 4.2, 4.4, 4.7

Proces recenzji i zatwierdzania jest kluczowym mechanizmem kontroli jakości Księgi Systemu. Każda zmiana — niezależnie od poziomu (MAJOR, MINOR, PATCH) — podlega recenzji, choć zakres i rygor recenzji skalują się proporcjonalnie do wagi zmiany.

Macierz zatwierdzania:

Typ zmiany	Recenzenci	Zatwierdzający	Min. liczba recenzji	SLA recenzji
MAJOR	Wszyscy właściciele rozdziałów + arch. bezpieczeństwa + compliance + zarząd	Komitet Bezpieczeństwa + Zarząd	5	15 dni roboczych
MINOR	Właściciele affected rozdziałów + arch. bezpieczeństwa	Architekt Główny	3	10 dni roboczych
PATCH	Właściciel rozdziału + peer review	Właściciel rozdziału	2	5 dni roboczych

Zasady recenzji:

Kompletność recenzji: Recenzent musi zweryfikować: (a) poprawność merytoryczną zmiany, (b) spójność z istniejącymi rozdziałami, (c) poprawność referencji krzyżowych, (d) poprawność metadanych (status, odbiorca, wpływ na baseline), (e) kompletność changelog.

Niezależność recenzji: Autor zmiany nie może być jednocześnie recenzentem zatwierdzającym. W przypadku MAJOR i MINOR — co najmniej jeden recenzent musi być spoza zespołu autora.

Dokumentacja recenzji: Każda recenzja musi być udokumentowana: komentarze recenzenta, odpowiedzi autora, rozstrzygnięcia sporów. Dokumentacja recenzji jest częścią CR.

Prawo weta: Architekt bezpieczeństwa oraz lider compliance posiadają prawo weta wobec dowolnej zmiany, jeżeli identyfikują ryzyko bezpieczeństwa lub niezgodność regulacyjną. Weto musi być uzasadnione pisemnie i może być uchylone wyłącznie przez Komitet Bezpieczeństwa.

Eskalacja braku konsensusu: W przypadku braku konsensusu między recenzentami, decyzja jest eskalowana do Architekta Głównego (dla MINOR/PATCH) lub Komitetu Bezpieczeństwa (dla MAJOR).

Automatyzacja recenzji: Tam gdzie to możliwe, elementy recenzji powinny być zautomatyzowane: walidacja referencji krzyżowych (czy wszystkie odwołania do rozdziałów prowadzą do istniejących sekcji), walidacja metadanych (czy każdy podrozdział posiada kompletny nagłówek), walidacja changelog (czy dla każdej zmiany istnieje wpis). Narzędzia automatyzacji powinny być utrzymywane jako część pipeline CI/CD dokumentacji.

4.7 Właściciele rozdziałów i odpowiedzialność redakcyjna

Status: [N] Normatywny Odbiorca: Architekt | Compliance Wpływ na baseline: Średni Powiązane rozdziały: 4.4, 4.6, 4.8

Każdy rozdział Księgi Systemu musi posiadać przypisanego właściciela (Chapter Owner) — osobę odpowiedzialną za merytoryczną poprawność, aktualność i spójność danego rozdziału z pozostałymi częściami dokumentu. Właścicielstwo rozdziału jest obowiązkiem, nie przywilejem — wiąże się z konkretnymi zobowiązaniami i odpowiedzialnością.

Obowiązki właściciela rozdziału:

Aktualność merytoryczna: Właściciel musi zapewnić, że treść rozdziału odzwierciedla aktualny stan architektury, wymagań i implementacji. Nieaktualny rozdział stanowi ryzyko — zespoły mogą podejmować decyzje na podstawie nieaktualnych informacji.

Recenzja zmian: Właściciel jest domyślnym recenzentem każdej zmiany dotyczącej jego rozdziału. Musi przejrzeć i zatwierdzić lub odrzucić zmianę w ramach SLA zdefiniowanego w sekcji 4.6.

Proaktywna aktualizacja: Właściciel nie czeka na zgłoszenie CR — proaktywnie identyfikuje potrzebę aktualizacji (np. po zmianie architektonicznej, po incydencie, po zmianie regulacyjnej) i inicjuje CR.

Spójność krzyżowa: Właściciel musi monitorować zmiany w rozdziałach powiązanych (pole „Powiązane rozdziały” w metadanych) i weryfikować, czy zmiany w powiązanych rozdziałach nie tworzą niespójności z jego rozdziałem.

Punkt kontaktowy: Właściciel jest pierwszym punktem kontaktowym dla pytań dotyczących interpretacji wymagań w jego rozdziale.

Zasada zastępowalności: Każdy właściciel rozdziału musi posiadać wyznaczonego zastępcę (Deputy Owner), który przejmuje obowiązki w przypadku nieobecności. Zastępca musi posiadać porównywalną kompetencję merytoryczną.

Macierz właścicielstwa:

Obszar rozdziałów	Rola właściciela	Rola zastępcy
Fundament dokumentu (Cz. I)	Architekt Główny	Lider Compliance
Architektura stref i gateway	Architekt Systemowy	Architekt Bezpieczeństwa
Bezpieczeństwo i kryptografia	Architekt Bezpieczeństwa	Lider SOC
Komunikacja (Matrix/Signal)	Architekt Systemowy	Lead Dev Backend
Izolacja i compute	Architekt Infrastruktury	Lead SRE
Operacje i monitoring	Lider SRE	Lider SOC
Compliance i certyfikacje	Lider Compliance	Architekt Bezpieczeństwa
Wdrożenia i onboarding	Lider Wdrożeń	Partner Lead

Przegląd właścicielstwa: Macierz właścicielstwa musi być przeglądana co pół roku i aktualizowana w przypadku zmian personalnych lub organizacyjnych. Rozdział bez przypisanego właściciela jest oznaczany tagiem [ORPHAN] i eskalowany do Architekta Głównego w ciągu 5 dni roboczych.

4.8 Polityka publikacji wersji wewnętrznych i zewnętrznych

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 1.4, 2.6, 2.7, 4.1, 4.5

Księga Systemu SYLION istnieje w dwóch wariantach dystrybucyjnych: wersja wewnętrzna (pełna) oraz wersja(-e) zewnętrzna(-e) (wyciągi). Polityka publikacji definiuje zasady tworzenia, dystrybucji i kontroli obu wariantów, zapewniając ochronę informacji wrażliwych przy jednoczesnym dostarczaniu odpowiedniej transparentności partnerom i klientom.

Wersja wewnętrzna (Internal Edition):

Pełna, niecenzurowana wersja Księgi Systemu zawierająca wszystkie rozdziały, w tym: szczegółowy model zagrożeń z TTP, pełną listę ryzyk rezydualnych, szczegóły architektoniczne wszystkich stref, konfiguracje referencyjne, scenariusze ataku i obrony, decyzje architektoniczne z pełnym kontekstem.

Dystrybucja: Wyłącznie dla zespołu wewnętrznego SYLION (pracownicy i dedykowani kontrahenci z NDA).

Klasyfikacja: POUFNE.

Format: Markdown w repozytorium z kontrolą wersji (Git) + renderowany PDF z watermarkiem personalnym.

Kontrola dostępu: Dostęp na zasadzie need-to-know. Każdy egzemplarz PDF jest personalnie watermarkowany (imię, data, numer kopii).

Wersja partnerska (Partner Edition):

Wyciąg z książki przeznaczony dla certyfikowanych partnerów wdrożeniowych. Zawiera: architekturę stref (na poziomie koncepcyjnym, bez szczegółów implementacyjnych), wymagania baseline [N], procedury wdrożeniowe i testy akceptacyjne, matrycę ról i odpowiedzialności, model odpowiedzialności współdzielonej.

Dystrybucja: Certyfikowani partnerzy z podpisanym NDA partnerskim.

Usunięte sekcje: Szczegółowe scenariusze ataku (SA-XXX), pełne ryzyka rezydualne (RR-XXX), konfiguracje referencyjne stref wewnętrznych (Strefa 4, 5), szczegóły stosu kryptograficznego (parametry HSM, hierarchia kluczy).

Format: PDF z watermarkiem organizacyjnym partnera.

Wersja kliencka (Customer Edition):

Wyciąg najwyższego poziomu abstrakcji, dostosowany do tieru klienta. Zawiera: opis architektury bezpieczeństwa na poziomie koncepcyjnym, gwarancje bezpieczeństwa dla danego tieru, model odpowiedzialności współdzielonej, SLA/SLO, mapowanie na standardy regulacyjne istotne dla klienta, raport compliance.

Dystrybucja: Klienci z podpisaną umową i NDA.

Dostosowanie: Wersja jest parametryzowana przez tier (STANDARD/PRO/STATE) — klient STATE otrzymuje bardziej szczegółowy wyciąg niż klient STANDARD.

Format: PDF z watermarkiem organizacyjnym klienta.

Zasady publikacji:

Każda wersja zewnętrzna musi być zatwierdzona przez compliance przed dystrybucją — weryfikacja, czy usunięte zostały wszystkie informacje wrażliwe.

Wersje zewnętrzne są generowane automatycznie z wersji wewnętrznej za pomocą narzędzia do filtrowania (build script), który usuwa sekcje oznaczone tagami [INTERNAL-ONLY], [PARTNER-ONLY] lub [CUSTOMER-TIER:STATE].

Wersje zewnętrzne nie mogą wyprzedzać wersji wewnętrznej — najpierw publikowana jest wersja wewnętrzna, następnie (w ciągu 10 dni roboczych) generowane i dystrybuowane są wersje zewnętrzne.

Rejestr dystrybucji: Każdy wydany egzemplarz (wewnętrzny i zewnętrzny) jest rejestrowany w Rejestrze Dystrybucji z informacją: odbiorca, wersja, data wydania, format, numer watermarku. Rejestr podlega audytowi.

Wycofanie egzemplarzy: W przypadku wycofania wersji (np. wykrycie wycieku informacji wrażliwej w wersji zewnętrznej), odbiorcy muszą zostać powiadomieni w ciągu 24 godzin, a wycofany egzemplarz musi być zniszczony lub oznaczony jako nieaktualny.

Koniec Części I — Fundament dokumentu, zakres i zasady interpretacji.

Następna część: CZĘŚĆ II — Kontekst strategiczny, pozycjonowanie i model zagrożeń (Rozdział 5–8).

Rozdział 5. Słownik pojęć, definicji i akronimów

Status: [N] Normatywny Odbiorca: Wszyscy uczestnicy projektu (architekci, deweloperzy, operatorzy, audytorzy, kadra zarządzająca, partnerzy) Wpływ na baseline:

Krytyczny Powiązane rozdziały: 1.1, 2.1, 3.1, 6.1, 7.1, 8.2, 9.3, 24.1

Niniejszy rozdział ustanawia kanoniczną terminologię systemu SYLION 3.0. Wszystkie dokumenty projektowe, specyfikacje techniczne, playbooki operacyjne, materiały certyfikacyjne oraz komunikacja wewnętrzna i zewnętrzna muszą stosować poniższe definicje w sposób jednolity. Odchylenie od terminologii normatywnej wymaga formalnej akceptacji Rady Architektury (Architecture Board) i odnotowania w Rejestrze Odchyień (Deviation Register).

Konwencja redakcyjna: definicje oznaczone symbolem [N] są normatywne — stosowanie alternatywnych terminów w dokumentacji jest zabronione. Definicje oznaczone [I] mają charakter informacyjny i służą wyłącznie celom edukacyjnym.

5.1 Słownik podstawowych pojęć produktowych

Status: [N] Normatywny Odbiorca: Wszyscy uczestnicy projektu Wpływ na baseline: Krytyczny Powiązane rozdziały: 1.1, 2.1, 7.1, 8.1, 9.1

Poniższe pojęcia stanowią fundament pojęciowy systemu SYLION 3.0 i muszą być rozumiane jednolicie przez wszystkich interesariuszy — od kadry zarządzającej przez architektów po operatorów i partnerów wdrożeniowych.

SYLION [N] — Platforma bezpiecznej komunikacji i pracy zdalnej oparta na modelu Thin Client z architekturą Zero Trust i mikrosegmentacją per-operator. SYLION stanowi ewolucję platformy FORTRESS (zob. §5.8) i jest projektowany z myślą o certyfikacji zgodnej z FIPS 140-3, Common Criteria oraz CNSA 2.0. Nazwa „SYLION” jest zastrzeżonym znakiem towarowym i musi być zapisywana wielkimi literami we wszystkich dokumentach oficjalnych.

Platforma [N] — Kompletny ekosystem technologiczny SYLION obejmujący: infrastrukturę chmurową (VPS, sieci, storage), warstwę orkiestracji (control plane), bramy bezpieczeństwa (G1/G2), środowiska operatorów (tenant environments), terminale klienckie oraz pełen stos zarządzania tożsamością, politykami i kryptografią. Platforma nie oznacza pojedynczego komponentu, lecz całość architektury multi-tenant z izolacją na poziomie mikroVM.

Operator [N] — Podmiot organizacyjny (firma, instytucja rządowa, jednostka wojskowa, organizacja pozarządowa), który nabywa licencję SYLION i zarządza własnym, logicznie izolowanym środowiskiem w ramach platformy. Operator posiada pełną suwerenność nad politykami bezpieczeństwa w granicach swojego tenantu, jednak musi przestrzegać minimalnych wymagań baseline narzuconych przez platformę (zob. Rozdział 9). Każdy operator jest identyfikowany unikalnym UUID i przypisany do jednego z trzech tierów: STANDARD, PRO lub STATE/SOVEREIGN.

Tenant [N] — Logiczna jednostka izolacji w architekturze multi-tenant SYLION, mapowana 1:1 na operatora. Tenant obejmuje: dedykowane zasoby obliczeniowe (mikroVM Firecracker), wydzielony segment sieci (mikrosegmentacja), własny zestaw polityk (policy engine), niezależne PKI (opcjonalnie z dedykowanym HSM), oraz izolowany storage. Granice tenanta są wymuszane sprzętowo (SEV-SNP/TDX) i sieciowo (eBPF, IPsec).

Środowisko operatora (Operator Environment) [N] — Suma wszystkich zasobów, workloadów, polityk i danych przypisanych do danego tenanta. Środowisko operatora obejmuje strefy bezpieczeństwa od Zone 2 do Zone 4 (zob. §5.2) i jest w pełni enkapsulowane — żaden workload jednego operatora nie może uzyskać dostępu do zasobów innego operatora. Środowisko jest tworzone procesem onboardingu i niszczone procesem offboardingu (zob. §5.4).

Workload [N] — Jednostka obliczeniowa uruchomiona w ramach środowiska operatora. Workload może przyjmować formę: mikroVM Firecracker (env-matrix, env-browser, env-office, env-crm, env-voice), rootless kontenera lub procesu w ramach istniejącej mikroVM. Każdy workload posiada przypisany profil bezpieczeństwa, limity zasobów (CPU, RAM, I/O, sieć) oraz jest monitorowany przez agenta telemetrycznego. Workloady są efemeryczne — ich stan nie przetrwa restartu, chyba że jest jawnie persystowany w VPS Vault.

Terminal [N] — Urządzenie końcowe użytkownika, działające wyłącznie jako punkt renderowania pikseli i przesyłania audio/wideo. Terminal w modelu SYLION nie przechowuje żadnych danych biznesowych — jest „cienkim oknem” do środowiska operatora. Terminal może być realizowany jako: dedykowane urządzenie sprzętowe (hardened endpoint), aplikacja desktopowa na OS ogólnego przeznaczenia lub aplikacja mobilna. Utrata lub kradzież terminala nie skutkuje wyciekami danych (polityka „Amnezja Urządzenia”, zob. §5.9).

Thin Client [N] — Model architektoniczny, w którym terminal pełni wyłącznie rolę interfejsu wejścia/wyjścia (renderowanie pikseli, przechwytywanie audio, transmisja wideo), a cała logika biznesowa, przetwarzanie danych i storage znajdują się w chmurowym środowisku operatora. W SYLION model Thin Client jest realizowany poprzez protokół zdalnego pulpitu z transmisją strumieniową do VPS Vault. Terminal nie wykonuje obliczeń na danych operatora — jedynie dekoduje strumień wizualny.

Session Broker [N] — Komponent control plane odpowiedzialny za: (a) uwierzytelnienie użytkownika i walidację kontekstu urządzenia, (b) wybór optymalnego węzła obliczeniowego dla sesji, (c) ustanowienie tunelu IPsec IKEv2 między terminalem a docelową mikroVM, (d) monitorowanie stanu sesji i wymuszanie timeoutów. Session Broker nie ma dostępu do treści sesji (zasada Blind Broker, zob. §5.8) — widzi wyłącznie metadane routingowe.

VPS Vault [N] — Chronione środowisko obliczeniowo-magazynowe w chmurze, stanowiące „cyfrowy sejf” operatora (zob. §5.9). VPS Vault obejmuje: (a) klaster mikroVM Firecracker uruchamianych na żądanie, (b) zaszyfrowany storage z kluczami zarządzanymi przez HSM, (c) mechanizmy Confidential Computing (SEV-SNP/TDX), (d) CDR gateway dla transferów plików. VPS Vault rezyduje w Zone 3 (zob. §5.2) i stanowi podstawową strefę przetwarzania danych operatora. Termin „Vault” podkreśla, że dane nigdy nie opuszczają chronionego środowiska w formie jawnej.

5.2 Słownik architektoniczny

Status: [N] Normatywny Odbiorca: Architekci, inżynierowie platform, DevSecOps, audytorzy Wpływ na baseline: Krytyczny Powiązane rozdziały: 2.2, 3.2, 8.2, 24.1, 25.1, 26.1, 27.1

Słownik architektoniczny definiuje komponenty, warstwy i wzorce projektowe stanowiące rdzeń systemu SYLION 3.0. Poprawne rozumienie tych pojęć jest warunkiem koniecznym dla pracy z dokumentacją techniczną części II–VII Księgi.

Split Gateway (Brama Dzielona) [N] — Dwuetapowa architektura bramy bezpieczeństwa, w której ruch sieciowy przechodzi sekwencyjnie przez dwa niezależne komponenty (G1 i G2), każdy odpowiedzialny za odrębny zestaw funkcji bezpieczeństwa. Podział na G1/G2 realizuje zasadę defense-in-depth i zapobiega sytuacji, w której kompromitacja pojedynczego komponentu daje atakującemu pełny dostęp do środowiska operatora. G1 i G2 muszą działać na oddzielnych węzłach obliczeniowych (fizycznych lub w oddzielnych TEE).

G1 (Gateway 1 / „Tarcza”) [N] — Pierwsza warstwa bramy bezpieczeństwa SYLION, odpowiedzialna za: terminację tunelu IPsec IKEv2 od terminala, wstępne uwierzytelnienie (certyfikat klientki + FIDO2), filtrowanie pakietów na poziomie L3/L4 (firewall stanowy), ochronę przed DDoS i atakami wolumetrycznymi, oraz przekazanie ruchu do G2. G1 operuje w Zone 1 (DMZ) i nie posiada dostępu do żadnych danych biznesowych operatora. G1 jest komponentem stateless — restart nie powoduje utraty stanu sesji (stan sesji jest zarządzany przez Session Broker).

G2 (Gateway 2 / „Mózg”) [N] — Druga warstwa bramy bezpieczeństwa, odpowiedzialna za: inspekcję aplikacyjną (L7), wymuszanie polityk ABAC/PBAC z policy engine, routing sesji do właściwej mikroVM w środowisku operatora, CDR (Content Disarm & Reconstruction) dla transferów plików, oraz logowanie zdarzeń bezpieczeństwa do SIEM. G2 operuje na granicy Zone 2/Zone 3 i posiada ograniczony, audytowalny dostęp do metadanych sesji. G2 podejmuje decyzje autoryzacyjne na podstawie polityk operatora wzbogaconych o kontekst ryzyka (device posture, geolokalizacja, pora dnia, anomalia behawioralna).

Zone 0 (Strefa Zero — Air-Gap / HSM) [N] — Najwyższy poziom bezpieczeństwa fizycznego. Zone 0 obejmuje: moduły HSM (Hardware Security Modules), generatory kluczy kryptograficznych, ceremonialne stacje offline do zarządzania root CA, oraz sealed recovery keys. Dostęp do Zone 0 wymaga fizycznej obecności, dual authorization i procedury break-glass. Zone 0 nie posiada żadnej łączności sieciowej — transfer materiału kryptograficznego odbywa się wyłącznie poprzez nośniki fizyczne z zachowaniem chain of custody.

Zone 1 (Strefa DMZ) [N] — Strefa buforowa między siecią publiczną (Internet) a infrastrukturą wewnętrzną SYLION. Zone 1 zawiera: G1, terminatory TLS/IPsec, loadbalancery, serwery DNS, endpointy healthcheck. Komponenty w Zone 1 są hardened, minimalistyczne (immutable images) i nie przechowują żadnych danych trwałych. Zone 1 jest jedyną strefą z ekspozycją na ruch publiczny.

Zone 2 (Strefa Control Plane) [N] — Strefa zarządzania i orkiestracji platformy. Zone 2 zawiera: Session Broker, Access Broker, Policy Engine, OIDC/SAML provider, provisioning engine, monitoring/alerting stack, API management. Komponenty Zone 2 zarządzają logiką platformy, ale nie przetwarzają danych biznesowych operatorów. Dostęp do Zone 2 jest ograniczony do ruchu z Zone 1 (po uwierzytelnieniu) oraz z Zone 5 (management plane).

Zone 3 (Strefa Danych Operatora / VPS Vault) [N] — Strefa przetwarzania i przechowywania danych biznesowych operatorów. Zone 3 zawiera: klastry mikroVM Firecracker z workloadami operatorów, zaszyfrowany storage, CDR processing pipeline, media relay (SFU). Każdy operator posiada logicznie i kryptograficznie izolowany segment w Zone 3. Dane w Zone 3 są szyfrowane at-rest (AES-256-GCM z kluczami z HSM) i in-use (SEV-SNP/TDX). Żaden komponent platformy spoza Zone 3 nie ma dostępu do danych operatora w formie jawnej.

Zone 4 (Strefa Logów i Audytu) [N] — Dedykowana strefa dla immutable logów, telemetrii bezpieczeństwa, nagrań audytowych i danych forensic. Zone 4 jest zaprojektowana zgodnie z modelem WORM (Write Once, Read Many) i hash chain — logi nie mogą być modyfikowane ani usunięte, nawet przez administratorów platformy. Zone 4 zasila SIEM/SOAR i stanowi źródło prawdy dla audytów zgodności i dochodzeń incydentowych.

Zone 5 (Strefa Zarządzania Platformą / Management Plane) [N] — Strefa administracyjna platformy, dostępna wyłącznie dla uprawnionych inżynierów SYLION poprzez dedykowane, hardened stacje robocze z uwierzytelnieniem wieloskładnikowym. Zone 5 zawiera: IaC pipelines, CI/CD, secret management (Vault), backup management, disaster recovery orchestration. Dostęp do Zone 5 podlega dual authorization i jest logowany w Zone 4.

MicroVM (Mikro-maszyna wirtualna) [N] — Lekka maszyna wirtualna uruchamiana przez hypervisor Firecracker, zaprojektowana do izolacji pojedynczego workloadu operatora. MicroVM startuje w czasie <150ms, posiada minimalistyczny kernel (zredukowana powierzchnia ataku), ograniczone urządzenia wirtualne (virtio-net, virtio-blk) i jest efemeryczna — jej stan nie przetrwa restartu, chyba że jawnie zapiszemy go do zaszyfrowanego storage. MicroVM zapewnia izolację silniejszą niż kontener, przy kosztach zbliżonych do kontenera.

Rootless Container (Kontener bezrootowy) [N] — Kontener OCI uruchomiony bez uprawnień root w przestrzeni nazw użytkownika (user namespace), z dodatkowymi ograniczeniami: seccomp profile, AppArmor/SELinux, brak możliwości eskalacji uprawnień (no_new_privs), read-only rootfs. W SYLION rootless containers mogą być wykorzystywane wewnątrz mikroVM dla dodatkowej warstwy izolacji (defense-in-depth), ale nigdy jako jedyny mechanizm izolacji tenanta.

Access Broker [N] — Komponent control plane odpowiedzialny za podejmowanie decyzji o udzieleniu lub odmowie dostępu do zasobów platformy na podstawie kontekstu uwierzytelnienia, polityk ABAC/PBAC i sygnałów ryzyka. Access Broker różni się od Session Broker tym, że operuje na poziomie autoryzacji zasobów (który workload, jaka akcja, jaki zakres danych), podczas gdy Session Broker zarządza cyklem życia sesji terminalowej.

Policy Engine (Silnik Polityk) [N] — Komponent wymuszający polityki bezpieczeństwa w czasie rzeczywistym. Policy Engine przyjmuje zapytania autoryzacyjne od Access Broker i G2, ewaluje je względem polityk operatora (wyrażonych w języku OPA/Rego lub równoważnym) wzbogaconych o kontekst (czas, lokalizacja, device posture, threat intelligence), i zwraca decyzję: allow, deny, step-up (wymagaj dodatkowego uwierzytelnienia) lub quarantine. Policy Engine musi działać z latencją <10ms (P99) i jest replikowany w trybie active-active.

Staging Zone (Strefa Przejściowa) [N] — Logiczny segment w architekturze SYLION, w którym dane wchodzące do środowiska operatora (pliki, łączniki, importy) podlegają procesowi CDR (Content Disarm & Reconstruction) przed dopuszczeniem do Zone 3. Staging Zone jest izolowana zarówno od Zone 1, jak i Zone 3 — kompromitacja Staging Zone nie daje dostępu do danych operatora. Pliki w Staging Zone są przetwarzane w efemerycznych mikroVM, które są niszczone po zakończeniu analizy.

CDR (Content Disarm and Reconstruction) [N] — Technologia bezpieczeństwa transferu plików, w której każdy plik przesyłany do/z środowiska operatora jest rozkładany na elementy składowe, analizowany pod kątem złośliwego kodu (makra, exploity, steganografia), a następnie rekonstruowany z bezpiecznych elementów. CDR w SYLION jest procesem destrukcyjnym — oryginalny plik binarny jest zastępowany zrekonstruowaną wersją. CDR operuje w Staging Zone i stanowi jedyny dopuszczalny kanał transferu plików do Zone 3.

Egress Proxy (Proxy Wyjściowy) [N] — Kontrolowany punkt wyjścia ruchu z środowiska operatora do sieci zewnętrznych (Internet). Egress Proxy wymusza polityki: whitelisty domen, inspekcja TLS (opcjonalna, konfigurowana per-operator), DLP (Data Loss Prevention), rate limiting. Cały ruch wychodzący z Zone 3 musi przejść przez Egress Proxy — bezpośredni dostęp do Internetu z workloadów operatora jest architektonicznie zablokowany.

Management Plane (Płaszczyzna Zarządzania) [N] — Warstwa administracyjna platformy SYLION, obejmująca narzędzia do: wdrażania infrastruktury (IaC), zarządzania konfiguracją, aktualizacji komponentów (OTA), zarządzania sekretami, monitorowania zdrowia platformy i orkestracji disaster recovery. Management Plane rezyduje w Zone 5 i jest odseparowany od control plane (Zone 2) oraz data plane (Zone 3). Dostęp wymaga dedykowanych credentiali, dual authorization i jest logowany w Zone 4.

Control Plane (Płaszczyzna Sterowania) [N] — Warstwa logiki platformy odpowiedzialna za: uwierzytelnienie, autoryzację, routing sesji, provisioning/deprovisioning zasobów, wymuszanie polityk, service discovery i health checking. Control Plane rezyduje w Zone 2 i pełni rolę „mózgu” operacyjnego platformy — podejmuje decyzje, ale nie dotyczy danych biznesowych operatorów.

Media Plane (Płaszczyzna Mediów) [N] — Warstwa transportu mediów w czasie rzeczywistym (audio, wideo, screensharing) w ramach komunikacji Matrix/VoIP. Media Plane obejmuje: SFU (Selective Forwarding Unit) w Zone 3, kodeki mediów, mechanizmy QoS, szyfrowanie end-to-end mediów (MLS/SFrame w trybie eksperymentalnym). Media Plane jest odseparowany od signaling plane (control) i data plane (storage).

Data Plane (Płaszczyzna Danych) [N] — Warstwa transportu i przetwarzania danych użytkowników w ramach środowisk operatorów. Data Plane obejmuje: ruch między terminalem a mikroVM (strumień pikseli, audio), ruch między workloadami w ramach jednego tenanta, oraz operacje na zaszyfrowanym storage. Data Plane rezyduje w Zone 3 i jest izolowany per-tenant na poziomie sieci (mikrosegmentacja eBPF) i kryptografii (unikalne klucze per-tenant z HSM).

5.3 Słownik bezpieczeństwa

Status: [N] Normatywny Odbiorca: Architekci bezpieczeństwa, SOC, audytorzy, deweloperzy, inżynierowie platform Wpływ na baseline: Krytyczny Powiązane rozdziały: 3.1, 3.3, 8.3, 9.2, 24.2, 30.1, 87.1, 98.1

Słownik bezpieczeństwa definiuje pojęcia kluczowe dla zrozumienia modelu zagrożeń, mechanizmów ochrony i polityk bezpieczeństwa SYLION 3.0. Pojęcia te stanowią wspólny język między zespołami Security, Engineering i Operations.

Zero Trust [N] — Model bezpieczeństwa, w którym żaden podmiot (użytkownik, urządzenie, workload, sieć) nie jest domyślnie zaufany, niezależnie od lokalizacji sieciowej. Każdy dostęp wymaga: (a) silnego uwierzytelnienia tożsamości, (b) walidacji stanu urządzenia (device posture), (c) autoryzacji kontekstowej opartej na politykach (ABAC/PBAC), (d) ciągłej walidacji w trakcie sesji (continuous verification). W SYLION Zero Trust jest realizowany przez: Split Gateway, Policy Engine, hardware attestation, mikrosegmentację i efemeryczność sesji. Architektura Zero Trust SYLION jest zgodna z NIST SP 800-207.

Mikrosegmentacja (Microsegmentation) [N] — Technika bezpieczeństwa sieciowego, w której każdy tenant, workload i usługa są izolowane we własnym, minimalnym segmencie sieciowym z precyzyjnymi regułami ruchu (allow-list). W SYLION mikrosegmentacja jest realizowana per-operator na poziomie: (a) eBPF (kernel-level, zero overhead), (b) IPsec (szyfrowanie inter-segment), (c) polityk OPA (reguły aplikacyjne). Mikrosegmentacja oznacza, że kompromitacja jednego workloadu nie daje automatycznie dostępu do żadnego innego workloadu — nawet w obrębie tego samego operatora, chyba że polityka operatora jawnie zezwala na komunikację.

Blast Radius (Promień Rażenia) [N] — Metryka bezpieczeństwa określająca maksymalny zakres szkód, jakie może wyrządzić kompromitacja pojedynczego komponentu, credentiala lub sesji. Architektura SYLION jest zaprojektowana z myślą o minimalizacji blast radius na każdym poziomie: kompromitacja terminala → brak danych (thin client), kompromitacja sesji → jedna mikroVM (efemeryczna), kompromitacja workloadu → jeden segment operatora (mikrosegmentacja), kompromitacja operatora → brak dostępu do innych operatorów (per-tenant izolacja kryptograficzna). Blast radius jest formalnie modelowany w ramach Threat Modelu (zob. Rozdział 30).

Lateral Movement (Ruch Boczny) [N] — Technika ataku, w której intruz, uzyskawszy dostęp do jednego komponentu systemu, próbuje rozszerzyć swój dostęp na inne komponenty, sieci lub dane. W SYLION lateral movement jest architektonicznie utrudniony przez: (a) mikrosegmentację — brak domyślnej łączności między segmentami, (b) efemeryczność mikroVM — brak trwałych credentiali w workloadach, (c) mTLS wszędzie — każda komunikacja wymaga wzajemnego uwierzytelnienia certyfikatami, (d) Zero Trust — brak zaufania opartego na lokalizacji sieciowej. Każda próba lateral movement generuje alerty w SIEM (Zone 4).

Confidential Computing (Poufne Przetwarzanie) [N] — Technologia sprzętowa zapewniająca ochronę danych w trakcie przetwarzania (in-use), obok tradycyjnej ochrony at-rest i in-transit. W SYLION Confidential Computing jest realizowane przez: AMD SEV-SNP (Secure Encrypted Virtualization — Secure Nested Paging) oraz Intel TDX (Trust Domain Extensions). Technologie te szyfrują pamięć RAM mikroVM kluczami zarządzanymi przez procesor — ani hypervisor, ani administrator platformy nie mają dostępu do danych w pamięci mikroVM operatora. Confidential Computing w SYLION stanowi warstwę defense-in-depth, nie absolutną granicę bezpieczeństwa (zob. §6.8 — decyzja oparta na analizie CVE SEV-SNP).

TEE (Trusted Execution Environment) [N] — Sprzętowo izolowane środowisko wykonawcze, w którym kod i dane są chronione przed dostępem z zewnątrz — w tym przed systemem operacyjnym hosta i hypervisorem. W kontekście SYLION TEE odnosi się do: AMD SEV-SNP VM, Intel TDX Trust Domain, lub (w przyszłości) ARM CCA Realm. TEE zapewnia: poufność (szyfrowanie pamięci), integralność (weryfikacja kodu) i atestację (zdalna weryfikacja stanu TEE).

Attestation (Atestacja) [N] — Proces kryptograficznej weryfikacji stanu i tożsamości komponentu sprzętowego lub programowego. W SYLION wyróżniamy: (a) Remote Attestation — zdalna weryfikacja stanu TEE (SEV-SNP/TDX) przez control plane przed dopuszczeniem workloadu do przetwarzania danych, (b) Platform Attestation — weryfikacja firmware'u i konfiguracji węzła obliczeniowego, (c) Hardware Heartbeat — ciągła weryfikacja tożsamości terminala (zob. niżej). Atestacja jest warunkiem koniecznym uruchomienia każdego workloadu w Zone 3.

FIDO2 [N] — Otwarty standard uwierzytelnienia oparty na kryptografii asymetrycznej i fizycznym tokenie (klucz sprzętowy, biometria urządzenia). W SYLION FIDO2 jest obowiązkowym mechanizmem uwierzytelnienia dla: wszystkich użytkowników tieru STATE/SOVEREIGN, administratorów platformy (Zone 5), oraz procedur break-glass. FIDO2 eliminuje hasła i jest odporny na phishing, replay i man-in-the-middle. W SYLION FIDO2 jest zintegrowany z Hardware Heartbeat — token FIDO2 pełni jednocześnie rolę identyfikatora urządzenia.

Hardware Heartbeat (Tętno Sprzętowe) [N] — Ciągły, kryptograficznie weryfikowany sygnał z terminala potwierdzający: (a) tożsamość fizycznego urządzenia (TPM-based attestation), (b) integralność firmware'u i OS terminala, (c) obecność autoryzowanego tokena FIDO2, (d) brak manipulacji sprzętowej (tamper detection, jeśli wspierane). Utrata Hardware Heartbeat skutkuje natychmiastowym zawieszeniem sesji i wymaga ponownego uwierzytelnienia. Hardware Heartbeat operuje z częstotliwością konfigurowalną per-operator (domyślnie co 30 sekund).

Kill Switch (Wyłącznik Awaryjny) [N] — Mechanizm umożliwiający natychmiastowe, nieodwracalne zablokowanie dostępu do środowiska operatora. Kill Switch może być aktywowany przez: (a) administratora operatora (via konsola lub API), (b) automatycznie przez Policy Engine (na podstawie reguł ryzyka), (c) zdalnie przez SOC SYLION (za zgodą operatora lub w ramach procedury incydentowej). Aktywacja Kill Switch powoduje: natychmiastowe zakończenie wszystkich sesji, revoke wszystkich tokenów, zamrożenie storage i opcjonalnie cryptographic destroy (zob. §5.9 — „Spopilenie”).

Duress PIN (PIN Wymuszony) [N] — Alternatywny kod uwierzytelnienia, który pozornie loguje użytkownika, ale jednocześnie: (a) wysyła cichy alarm do SOC operatora, (b) prezentuje ograniczone lub sfalszowane dane (decoy environment), (c) loguje wszystkie akcje w sesji duress do Zone 4. Duress PIN jest przeznaczony dla scenariuszy, w których użytkownik jest fizycznie przymuszany do udzielenia dostępu. Implementacja Duress PIN jest opcjonalna na poziomie operatora, rekomendowana dla tieru STATE/SOVEREIGN.

Immutable Infrastructure (Infrastruktura Niemutowalna) [N] — Paradigmat zarządzania infrastrukturą, w którym komponenty (obrazy VM, kontenery, konfiguracja) nigdy nie są modyfikowane po wdrożeniu — zamiast aktualizacji, wdraża się nową, przetestowaną wersję, a starą niszczy. W SYLION immutable infrastructure obejmuje: (a) obrazy mikroVM Firecracker (budowane w CI/CD, podpisywane cyfrowo, weryfikowane przed startem), (b) konfigurację G1/G2 (dostarczaną jako sealed artifacts), (c) obrazy terminali. Immutability eliminuje configuration drift i znacząco utrudnia persystencję atakującego.

WORM (Write Once, Read Many) [N] — Model storage, w którym dane po zapisaniu nie mogą być modyfikowane ani usunięte przez określony czas (retention period). W SYLION WORM jest stosowany w Zone 4 dla logów bezpieczeństwa, logów audytu, nagrań sesji i dowodów forensic. WORM jest wymuszany na poziomie storage (object lock) i weryfikowany przez hash chain — każdy wpis w logu zawiera kryptograficzny hash poprzedniego wpisu, co uniemożliwia niezauważalne usunięcie lub modyfikację.

Hash Chain (Łańcuch Hashów) [N] — Struktura danych, w której każdy kolejny rekord zawiera kryptograficzny hash (SHA-3 lub BLAKE3) poprzedniego rekordu, tworząc nierozzerwalny łańcuch integralności. W SYLION hash chain jest stosowany w: logach bezpieczeństwa (Zone 4), rejestrze zmian polityk, rejestrze operacji kryptograficznych (HSM audit log). Przerwanie hash chain (brak spójności hashów) jest automatycznie wykrywane i traktowane jako incydent bezpieczeństwa klasy Critical.

Sealed Recovery Key (Zapiecztowany Klucz Odzyskiwania) [N] — Klucz kryptograficzny przeznaczony do odzyskania dostępu do środowiska operatora w scenariuszach katastroficznych (utrata HSM, disaster recovery). Sealed Recovery Key jest generowany w ceremonii offline (Zone 0), dzielony na fragmenty (Shamir's Secret Sharing, minimum k-z-n), a każdy fragment jest przechowywany w osobnej lokalizacji fizycznej przez odrębnych powierników (custodians). Odtworzenie klucza wymaga zgromadzenia minimalnej liczby fragmentów i procedury dual authorization.

Dual Authorization (Podwójna Autoryzacja) [N] — Mechanizm kontroli dostępu wymagający zatwierdzenia przez co najmniej dwie niezależne, uprawnione osoby dla operacji krytycznych. W SYLION dual authorization jest obowiązkowa dla: (a) dostępu do Zone 0, (b) aktywacji Kill Switch na poziomie platformy, (c) odtworzenia Sealed Recovery Key, (d) modyfikacji polityk normatywnych baseline, (e) eksportu danych z Zone 4. Dual authorization jest realizowana technicznie (wymagane dwa odrębne credentiala) i proceduralnie (separation of duties).

Crown Jewels (Klejnoty Koronne) [N] — Aktywa o najwyższej wartości i krytyczności w architekturze SYLION, których kompromitacja stanowiłaby egzystencjalne zagrożenie dla platformy lub operatorów. Crown Jewels SYLION obejmują: (a) klucze root CA w HSM (Zone 0), (b) Sealed Recovery Keys, (c) klucze szyfrowania storage operatorów, (d) polityki normatywne baseline, (e) kod źródłowy certifiable core. Crown Jewels podlegają najwyższym rygorom ochrony — fizyczna izolacja, dual authorization, ciągły monitoring, procedury ceremonialne.

5.4 Słownik operacyjny

Status: [N] Normatywny Odbiorca: Zespoły Operations, DevSecOps, Service Delivery, Support Wpływ na baseline: Wysoki Powiązane rozdziały: 9.4, 83.1, 84.1, 85.1, 93.1, 94.1, 109.1

Słownik operacyjny definiuje procesy i procedury cyklu życia operatora, środowiska i użytkownika w platformie SYLION 3.0. Terminologia ta jest obowiązkowa w playbookach, runbookach i dokumentacji operacyjnej.

Onboarding [N] — Formalny, wieloetapowy proces wdrożenia nowego operatora na platformę SYLION, obejmujący: (a) podpisanie umowy i klasyfikację tieru (STANDARD/PRO/STATE), (b) provisioning środowiska (tenant creation, network segmentation, PKI issuance), (c) konfigurację polityk bezpieczeństwa (policy baseline + customization), (d) integrację z systemami operatora (IdP, SIEM forwarding), (e) szkolenie administratorów operatora, (f) User Acceptance Testing, (g) aktywację produkcyjną. Onboarding jest procesem audytowalnym — każdy krok jest logowany w Zone 4 z hash chain.

Offboarding [N] — Formalny proces usunięcia operatora z platformy SYLION, obejmujący: (a) zakończenie wszystkich aktywnych sesji, (b) revoke wszystkich certyfikatów i tokenów, (c) eksport danych operatora (jeśli wymagany umową), (d) cryptographic destroy kluczy szyfrowania storage operatora w HSM, (e) bezpieczne zniszczenie mikroVM i storage (crypto-erase + overwrite), (f) archiwizację logów audytu (Zone 4, retention period per regulacja), (g) potwierdzenie completion z checklist audytowym. Offboarding jest nieodwracalny po etapie (d) — klucze zniszczone w HSM nie mogą być odtworzone.

Provisioning [N] — Automatyczny proces tworzenia i konfiguracji zasobów technicznych dla operatora lub użytkownika: alokacja mikroVM, tworzenie segmentów sieciowych, emisja certyfikatów PKI, konfiguracja polityk w Policy Engine, tworzenie kont w IdP. Provisioning jest realizowany przez IaC (Infrastructure as Code)

pipeline w Zone 5, jest idempotentny (wielokrotne wykonanie daje ten sam rezultat) i w pełni audytowalny. Czas provisioning nowego środowiska operatora nie powinien przekraczać 30 minut (SLO).

Deprovisioning [N] — Proces odwrotny do provisioning — usunięcie zasobów technicznych: zniszczenie mikroVM, usunięcie segmentów sieciowych, revoke certyfikatów, usunięcie polityk, dezaktywacja kont. Deprovisioning musi być kompletny — nie mogą pozostać „osierocone” zasoby (orphaned resources), które zwiększałyby powierzchnię ataku. Deprovisioning jest automatycznie walidowany przez skrypt audytowy, który weryfikuje usunięcie wszystkich zasobów powiązanych z danym operatorem/użytkownikiem.

Rebuild (Przebudowa) [N] — Proces zniszczenia istniejącej instancji komponentu (mikroVM, kontenera, węzła) i zastąpienia jej nową instancją zbudowaną z immutable image. Rebuild jest standardową procedurą SYLION zamiast „naprawy” — jeśli komponent wykazuje nieprawidłowe zachowanie, jest niszczone i budowany od nowa (principle of disposability). Rebuild automatycznie odbywa się: (a) po każdej aktualizacji obrazu, (b) po wykryciu anomalii przez monitoring, (c) na żądanie operatora, (d) po przekroczeniu maksymalnego czasu życia instancji (configurable TTL).

Revoke (Unieważnienie) [N] — Natychmiastowe unieważnienie credentiala (certyfikatu, tokena, klucza API, sesji). W SYLION revoke jest operacją krytyczną, realizowaną w sposób: (a) natychmiastowy (propagacja <5 sekund do wszystkich punktów wymuszania), (b) kompletny (credential jest dodawany do CRL/OCSP i revocation cache na G1/G2), (c) audytowalny (logowany w Zone 4 z kontekstem: kto, co, dlaczego, kiedy). Revoke jest nieodwracalny — unieważniony credential nie może być „przywrócony”; konieczna jest emisja nowego.

Re-enrollment (Ponowna Rejestracja) [N] — Proces ponownego zarejestrowania użytkownika lub urządzenia po unieważnieniu credentiali. Re-enrollment obejmuje: (a) weryfikację tożsamości użytkownika (out-of-band, np. wizyta osobista lub wideokonferencja z weryfikacją dokumentu), (b) emisję nowych certyfikatów i tokenów, (c) re-provisioning terminala (wgranie nowego profilu), (d) ponowne powiązanie tokena FIDO2. Re-enrollment jest wymagany po: kradzieży/utracie terminala, podejrzeniu kompromitacji credentiali, procedurze Kill Switch, oraz okresowej rotacji (jeśli skonfigurowana).

Playbook [N] — Dokument proceduralny opisujący sekwencję kroków dla powtarzalnego procesu operacyjnego lub reakcji na incydent. Playbook w SYLION zawiera: (a) warunki wejściowe (trigger), (b) wymagane role i uprawnienia, (c) sekwencję kroków z decyzjami warunkowymi, (d) oczekiwane wyniki, (e) kryteria eskalacji, (f) checklist weryfikacyjny. Playbooki są wersjonowane w repozytorium Git, podlegają review przez Security Team i są testowane w ćwiczeniach (tabletop exercises) minimum raz na kwartał.

Runbook [N] — Szczegółowy, techniczny przewodnik wykonawczy dla konkretnej operacji infrastrukturalnej. Runbook różni się od playbooksa poziomem szczegółowości — zawiera: dokładne komendy, parametry konfiguracyjne, oczekiwane output, instrukcje rollback i kontakt eskalacyjny. Runbooki w SYLION powinny być zautomatyzowane (executable runbooks) w maksymalnym możliwym stopniu, z ręcznymi krokami ograniczonymi do decyzji wymagających ludzkiego osądu.

Break-Glass (Awaryjne Nadanie Uprawnień) [N] — Procedura awaryjna umożliwiająca uzyskanie podwyższonych uprawnień w sytuacjach krytycznych, gdy normalne ścieżki autoryzacji są niedostępne lub zbyt wolne. Break-glass w SYLION wymaga: (a) uzasadnienia (reason code), (b) dual authorization (dwie osoby z listy break-glass custodians), (c) ograniczenia czasowego (time-boxed access, domyślnie 4 godziny), (d) pełnego logowania wszystkich akcji w Zone 4, (e) obowiązkowego post-mortem po zakończeniu. Nadużycie procedury break-glass jest traktowane jako incydent bezpieczeństwa.

Freeze (Zamrożenie) [N] — Okres, w którym zmiany w infrastrukturze produkcyjnej są zabronione, z wyjątkiem poprawek bezpieczeństwa klasy Critical i procedur break-glass. Freeze jest stosowany: (a) przed i po major release (stabilization freeze), (b) w okresach wysokiego ryzyka (np. święta, wybory — dla klientów STATE), (c) w trakcie audytu zewnętrznego. Naruszenie freeze wymaga zatwierdzenia przez VP Engineering i jest logowane jako deviation.

Maintenance Window (Okno Serwisowe) [N] — Zaplanowany, komunikowany z wyprzedzeniem przedział czasowy, w którym dozwolone są zmiany infrastrukturalne mogące skutkować przerwą w dostępności. Maintenance Window w SYLION jest: (a) planowane z minimum 72-godzinnym wyprzedzeniem (STANDARD) lub 168-godzinnym (STATE/SOVEREIGN), (b) komunikowane operatorom via dedykowany kanał statusowy, (c) ograniczone czasowo (domyślnie max 4 godziny), (d) objęte rollback planem. Tier STATE/SOVEREIGN może negocjować indywidualne okna serwisowe w umowie SLA.

5.5 Słownik zgodności i audytu

Status: [N] Normatywny Odbiorca: Compliance Officers, audytorzy, architekci bezpieczeństwa, kadra zarządzająca Wpływ na baseline: Krytyczny Powiązane rozdziały: 3.4, 9.5, 10.1, 87.1, 88.1, 89.1

Słownik zgodności definiuje normy, standardy i frameworki regulacyjne, do których SYLION 3.0 jest projektowany jako zgodny lub certyfikowalny. Poprawne rozumienie tych pojęć jest warunkiem koniecznym dla pracy z dokumentacją certyfikacyjną i audytową.

FIPS 140-3 [N] — Standard federalny USA (NIST) określający wymagania bezpieczeństwa dla modułów kryptograficznych. FIPS 140-3 definiuje cztery poziomy bezpieczeństwa (Level 1–4), obejmujące: walidację algorytmów, ochronę kluczy, fizyczną ochronę modułu, testy samoweryfikacyjne. W SYLION FIPS 140-3 Level 2 (minimum) jest wymagany dla modułów HSM w Zone 0 oraz bibliotek kryptograficznych w certifiable core. Tier STATE/SOVEREIGN powinien dążyć do FIPS 140-3 Level 3.

Common Criteria (CC) [N] — Międzynarodowy standard (ISO/IEC 15408) oceny bezpieczeństwa produktów IT. Common Criteria definiuje: Protection Profile (PP) — wymagania bezpieczeństwa dla klasy produktów, Security Target (ST) — deklaracja bezpieczeństwa konkretnego produktu, Evaluation Assurance Level (EAL 1–7) — głębokość ewaluacji. SYLION jest projektowany z myślą o certyfikacji CC, z certifiable core mapowanym na Security Target. Docelowy poziom: EAL4+ dla komponentów core.

FedRAMP (Federal Risk and Authorization Management Program) [N] — Program rządu USA standaryzujący ocenę bezpieczeństwa usług chmurowych dla agencji federalnych. FedRAMP definiuje trzy poziomy bazowe (Low, Moderate, High) odpowiadające kategoryzacji FIPS 199. SYLION jest projektowany z uwzględnieniem kontroli FedRAMP High jako referencyjnego frameworka bezpieczeństwa chmurowego, nawet dla wdrożeń poza jurysdykcją USA.

CNSA 2.0 (Commercial National Security Algorithm Suite 2.0) [N] — Zestaw algorytmów kryptograficznych zatwierdzonych przez NSA dla ochrony informacji niejawnych (National Security Systems). CNSA 2.0 definiuje harmonogram przejścia na kryptografię postquantum (PQC): do 2030 — obowiązkowe PQC dla software/firmware, do 2033 — obowiązkowe PQC dla sieci (w tym IPsec). SYLION stosuje algorytmy CNSA 2.0 (ML-KEM, ML-DSA, AES-256, SHA-384+) i przygotowuje crypto-agile stack do pełnego przejścia PQC. Wybór IPsec IKEv2 zamiast WireGuard jest bezpośrednio podyktowany wymaganiami CNSA 2.0 (zob. §6.8).

SOC 2 (Service Organization Control 2) [N] — Framework audytowy AICPA dla organizacji świadczących usługi, oparty na pięciu Trust Service Criteria: Security, Availability, Processing Integrity, Confidentiality, Privacy. SYLION dąży do raportu SOC 2 Type II (potwierdzenie skuteczności kontroli w czasie) jako minimum dla wszystkich tierów. Raport SOC 2 jest udostępniany operatorom pod NDA.

ISO 27001 [N] — Międzynarodowy standard systemu zarządzania bezpieczeństwem informacji (ISMS). ISO 27001 definiuje wymagania dla: ustanowienia, wdrożenia, utrzymania i ciągłego doskonalenia ISMS. SYLION implementuje kontrole z Aneksu A ISO 27001:2022 i dąży do certyfikacji ISO 27001 jako uzupełnienia SOC 2. ISO 27001 jest szczególnie istotny dla operatorów europejskich.

DISA STIG (Defense Information Systems Agency Security Technical Implementation Guide) [N] — Szczegółowe wytyczne konfiguracji bezpieczeństwa dla produktów IT stosowanych w Departamencie Obrony USA. STIG zawiera konkretne, weryfikowalne reguły konfiguracji (findings) z kategoryzacją severity (CAT I/II/III). SYLION stosuje odpowiednie STIG jako baseline konfiguracji dla: systemów operacyjnych, baz danych, serwerów webowych i infrastruktury sieciowej. Zgodność ze STIG jest walidowana automatycznie przez narzędzia SCAP.

CSfC (Commercial Solutions for Classified) [N] — Program NSA umożliwiający wykorzystanie komercyjnych produktów IT do ochrony informacji niejawnych, pod warunkiem spełnienia zdefiniowanych wymagań architektonicznych (Capability Packages). CSfC wymaga stosowania „warstwowej” kryptografii (layered encryption) z dwóch niezależnych, zatwierdzonych produktów. Architektura Split Gateway SYLION (G1/G2) jest zaprojektowana z uwzględnieniem wymagań CSfC dla Mobile Access Capability Package.

NIAP (National Information Assurance Partnership) [N] — Amerykański program oceny produktów IT pod kątem Common Criteria, zarządzany przez NSA. NIAP publikuje Protection Profiles (PP) i prowadzi listę zatwierdzonych produktów (PCL — Products Compliant List). SYLION dąży do ewaluacji NIAP dla komponentów VPN (PP-Module for VPN Gateway) i klienta (PP for Application Software).

GDPR (General Data Protection Regulation) [N] — Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 regulujące ochronę danych osobowych w Unii Europejskiej. GDPR definiuje wymagania dla: przetwarzania danych osobowych, praw osób (dostęp, usunięcie, przenoszenie), notyfikacji o naruszeniach, oceny skutków (DPIA), oraz roli administratora i procesora danych. SYLION implementuje kontrole techniczne wspierające zgodność operatorów z GDPR: szyfrowanie, pseudonimizacja, prawo do usunięcia (cryptographic destroy), audit trail.

RODO [N] — Polska implementacja GDPR — Rozporządzenie o Ochronie Danych Osobowych. W kontekście SYLION RODO i GDPR są stosowane zamiennie, z uwzględnieniem specyfiki polskiego prawa (ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych) w zakresie organu nadzorczego (UODO) i kar administracyjnych. Operatorzy polscy muszą uwzględnić wymagania RODO w konfiguracji polityk retencji danych i lokalizacji przetwarzania.

Certifiable Core (Rdzeń Certyfikowalny) [N] — Wydzielony, minimalny zbiór komponentów SYLION podlegających formalnej certyfikacji (Common Criteria, FIPS, NIAP). Certifiable core obejmuje: moduł kryptograficzny, stos IPsec IKEv2, mechanizm uwierzytelnienia (FIDO2 + PKI), Policy Engine (core rules), Session Broker (core logic). Certifiable core jest: (a) minimalny (minimalna powierzchnia ataku), (b) stabilny (rzadkie zmiany, rygorystyczny change management), (c) formalnie weryfikowalny (code review, static analysis, fuzzing, penetration testing). Zmiany w certifiable core wymagają zatwierdzenia Architecture Board i re-assessment wpływu na certyfikację.

Autonomous Module (Moduł Autonomiczny) [N] — Komponent SYLION funkcjonujący poza certifiable core, podlegający standardowym procesom jakości (CI/CD, testy, code review), ale nie wymagający formalnej certyfikacji. Moduły autonomiczne obejmują: env-browser, env-office, env-crm, integracje z systemami zewnętrznymi, dashboards, narzędzia administracyjne. Moduły autonomiczne mogą być aktualizowane niezależnie od certifiable core, z zachowaniem kompatybilności API. Granica między certifiable core a autonomous modules jest formalnie zdefiniowana w dokumencie RSD (Reference Security Document).

5.6 Akronimy techniczne

Status: [N] Normatywny Odbiorca: Wszyscy uczestnicy techniczni projektu Wpływ na baseline: Średni Powiązane rozdziały: 5.1–5.5, 5.7, 5.8

Poniższy wykaz obejmuje akronimy techniczne stosowane w dokumentacji SYLION 3.0. Przy pierwszym wystąpieniu w każdym dokumencie akronim musi być rozwinięty w pełną formę, a następnie stosowany w formie skróconej.

Akronim	Pełna nazwa	Kontekst w SYLION
IPsec	Internet Protocol Security	Protokół szyfrowania komunikacji sieciowej; podstawowy mechanizm tunelowania SYLION (zamiast WireGuard — zob. §6.8)
IKEv2	Internet Key Exchange version 2	Protokół negocjacji kluczy dla IPsec; zdefiniowany w RFC 7296; wybrany ze względu na zgodność CNSA 2.0 i wsparcie PQC (RFC 9370)
mTLS	Mutual Transport Layer Security	Wzajemne uwierzytelnienie certyfikatami TLS; obowiązkowe dla komunikacji między komponentami wewnętrznymi SYLION
HSM	Hardware Security Module	Dedykowany moduł sprzętowy do zarządzania kluczami kryptograficznymi; rezyduje w Zone 0
PKI	Public Key Infrastructure	Infrastruktura klucza publicznego; SYLION utrzymuje wewnętrzną PKI z root CA w HSM
PQC	Post-Quantum Cryptography	Algorytmy kryptograficzne odporne na ataki komputerów kwantowych
ML-KEM	Module-Lattice-based Key-Encapsulation Mechanism	Algorytm PQC wymiany kluczy (dawniej CRYSTALS-Kyber); NIST FIPS 203
ML-DSA	Module-Lattice-based Digital Signature Algorithm	Algorytm PQC podpisu cyfrowego (dawniej CRYSTALS-Dilithium); NIST FIPS 204
SLH-DSA	Stateless Hash-based Digital Signature Algorithm	Algorytm PQC podpisu cyfrowego (dawniej SPHINCS+); NIST FIPS 205; stosowany jako backup dla ML-DSA
SEV-SNP	Secure Encrypted Virtualization — Secure Nested Paging	Technologia AMD zapewniająca Confidential Computing na poziomie VM
TDX	Trust Domain Extensions	Technologia Intel zapewniająca Confidential Computing (Trust Domains)
CDR	Content Disarm and Reconstruction	Technologia bezpieczeństwa transferu plików; dekonstrukcja i rekonstrukcja plików w Staging Zone
SIEM	Security Information and Event Management	System zbierania, korelacji i analizy zdarzeń bezpieczeństwa; zasilany z Zone 4
SOAR	Security Orchestration, Automation and Response	Platforma automatyzacji odpowiedzi na incydenty bezpieczeństwa; integrowana z SIEM
RBAC	Role-Based Access Control	Model kontroli dostępu oparty na rolach; stosowany jako warstwa bazowa
ABAC	Attribute-Based Access Control	Model kontroli dostępu oparty na atrybutach; rozszerzenie RBAC o kontekst
PBAC	Policy-Based Access Control	Model kontroli dostępu oparty na politykach; ewaluowanych przez Policy Engine (OPA/Rego)

OPA	Open Policy Agent	Silnik polityk open-source; podstawa Policy Engine SYLION
OIDC	OpenID Connect	Protokół uwierzytelniania oparty na OAuth 2.0; stosowany do federacji tożsamości z IdP operatora
SAML	Security Assertion Markup Language	Standard wymiany asercji uwierzytelniania/autoryzacji; wspierany jako alternatywa dla OIDC
JWT	JSON Web Token	Format tokenów; stosowany w komunikacji między komponentami control plane
gRPC	gRPC Remote Procedure Call	Framework komunikacji międzyserwisowej; stosowany w control plane SYLION
eBPF	Extended Berkeley Packet Filter	Technologia kernel-level do programowalnego filtrowania pakietów i obserwacji; podstawa mikrosegmentacji sieciowej
SBOM	Software Bill of Materials	Lista wszystkich komponentów oprogramowania; obowiązkowa dla każdego artefaktu w SYLION
SCA	Software Composition Analysis	Analiza zależności oprogramowania pod kątem znanych podatności (CVE); element CI/CD pipeline
IaC	Infrastructure as Code	Zarządzanie infrastrukturą przez deklaracyjny kod; jedyny dopuszczalny sposób modyfikacji infrastruktury SYLION
OTA	Over-the-Air (update)	Zdalne aktualizacje firmware/oprogramowania terminali; wymagane podpisanie cyfrowe i weryfikacja
QoS	Quality of Service	Mechanizmy priorytetyzacji ruchu sieciowego; konfigurowane per-workload
SLI	Service Level Indicator	Mierzalna metryka poziomu usługi (np. latencja P99, dostępność)
SLO	Service Level Objective	Docelowa wartość SLI (np. dostępność 99.95%)
SLA	Service Level Agreement	Umowne zobowiązanie dotyczące poziomu usługi; z konsekwencjami za naruszenie
RPO	Recovery Point Objective	Maksymalna akceptowalna utrata danych (wyrażona w czasie); definiuje częstotliwość backupów
RTO	Recovery Time Objective	Maksymalny akceptowalny czas przywrócenia usługi po awarii
HA	High Availability	Wysoka dostępność; architektura odporna na awarię pojedynczego komponentu
DR	Disaster Recovery	Odyskiwanie po katastrofie; procedury przywrócenia usługi po zdarzeniu losowym
BCP	Business Continuity Plan	Plan ciągłości działania; nadrzędny dokument obejmujący HA i DR

5.7 Akronimy regulacyjne i certyfikacyjne

Status: [N] Normatywny Odbiorca: Compliance Officers, audytorzy, kadra zarządzająca, partnerzy Wpływ na baseline: Średni Powiązane rozdziały: 5.5, 9.5, 87.1, 88.1

Poniższy wykaz obejmuje akronimy regulacyjne i certyfikacyjne stosowane w kontekście zgodności platformy SYLION 3.0.

Akronim	Pełna nazwa	Kontekst w SYLION
FIPS	Federal Information Processing Standards	Rodzina standardów NIST; FIPS 140-3 (kryptografia), FIPS 199 (kategoryzacja), FIPS 200 (minimalne wymagania)
NIST	National Institute of Standards and Technology	Instytut standardów USA; źródło SP 800-207 (Zero Trust), SP 800-63 (tożsamość), SP 800-53 (kontrolne)
CC	Common Criteria (ISO/IEC 15408)	Standard certyfikacji bezpieczeństwa IT; docelowy framework certyfikacji SYLION
EAL	Evaluation Assurance Level	Poziom ewaluacji CC (1–7); SYLION dąży do EAL4+ dla certifiable core
PP	Protection Profile	Profil ochrony CC; definiuje wymagania bezpieczeństwa dla klasy produktów
ST	Security Target	Cel bezpieczeństwa CC; deklaracja bezpieczeństwa konkretnego produktu SYLION
NIAP	National Information Assurance Partnership	Program oceny CC zarządzany przez NSA; publikuje PP i PCL
PCL	Products Compliant List	Lista produktów zatwierdzonych przez NIAP
CSfC	Commercial Solutions for Classified	Program NSA; komercyjne produkty do ochrony informacji niejawnych
CP	Capability Package (CSfC)	Pakiet wymagań architektonicznych CSfC (np. Mobile Access CP)
FedRAMP	Federal Risk and Authorization Management Program	Program certyfikacji usług chmurowych dla agencji federalnych USA
ATO	Authority to Operate	Formalna autoryzacja do uruchomienia systemu; wynik procesu FedRAMP/RMF
P-ATO	Provisional Authority to Operate	Tymczasowe ATO wydawane przez JAB w procesie FedRAMP
JAB	Joint Authorization Board	Rada autoryzacyjna FedRAMP (DoD, DHS, GSA)
RMF	Risk Management Framework	Framework zarządzania ryzykiem NIST (SP 800-37); proces certyfikacji DoD
STIG	Security Technical Implementation Guide	Wytyczne konfiguracji bezpieczeństwa DISA
SCAP	Security Content Automation Protocol	Protokół automatycznej walidacji zgodności ze STIG
CNSA	Commercial National Security Algorithm (Suite)	Zestaw algorytmów kryptograficznych zatwierdzonych przez NSA
SOC	Service Organization Control	Framework audytowy AICPA; SOC 2 Type II jest docelowy dla SYLION
ISO	International Organization for Standardization	Organizacja normalizacyjna; ISO 27001 (ISMS), ISO 27017 (chmura), ISO 27018 (PII w chmurze)
ISMS	Information Security Management System	System zarządzania bezpieczeństwem informacji; wymagany przez ISO 27001
GDPR	General Data Protection Regulation	Rozporządzenie UE 2016/679 o ochronie danych osobowych
RODO	Rozporządzenie o Ochronie Danych Osobowych	Polska implementacja GDPR
UODO	Urząd Ochrony Danych Osobowych	Polski organ nadzorczy ds. ochrony danych osobowych
DPIA	Data Protection Impact Assessment	Ocena skutków dla ochrony danych; wymagana przez GDPR Art. 35
DPA	Data Processing Agreement	Umowa powierzenia przetwarzania danych; wymagana między SYLION a operatorem
CVE	Common Vulnerabilities and Exposures	System identyfikacji podatności bezpieczeństwa
CWE	Common Weakness Enumeration	Klasyfikacja słabości oprogramowania

NVD	National Vulnerability Database	Baza danych podatności NIST; źródło scoringu CVSS
CVSS	Common Vulnerability Scoring System	System oceny krytyczności podatności (0.0–10.0)
SBOM	Software Bill of Materials	Lista komponentów oprogramowania; wymagana przez Executive Order 14028
VEX	Vulnerability Exploitability eXchange	Dokument opisujący status exploitability podatności w kontekście konkretnego produktu
CISA	Cybersecurity and Infrastructure Security Agency	Agencja cyberbezpieczeństwa USA; publikuje KEV (Known Exploited Vulnerabilities)
ENS	Esquema Nacional de Seguridad	Hiszpański framework bezpieczeństwa; referencyjny dla operatorów hiszpańskich
BSI	Bundesamt für Sicherheit in der Informationstechnik	Niemiecki urząd bezpieczeństwa IT; IT-Grundschutz jako referencja
ANSSI	Agence nationale de la sécurité des systèmes d'information	Francuski urząd cyberbezpieczeństwa; certyfikacja CSPN

5.8 Terminologia zastrzeżona i pojęcia wewnętrzne SYLION

Status: [N] Normatywny Odbiorca: Wszyscy uczestnicy projektu wewnętrzni Wpływ na baseline: Wysoki Powiązane rozdziały: 5.1, 5.2, 5.3, 7.1, 24.1

Poniższe pojęcia są terminologią wewnętrzną projektu SYLION. Ich stosowanie jest obowiązkowe w komunikacji wewnętrznej, specyfikacjach technicznych i dokumentacji projektowej. Niektóre z tych terminów nie powinny pojawiać się w materiałach marketingowych skierowanych do klientów końcowych (zob. §5.9 — mapowanie terminów).

env-matrix [N] — Typ workloadu mikroVM dedykowany usłudze komunikacyjnej opartej na protokole Matrix. Env-matrix obejmuje: serwer homeserver Matrix (Synapse lub Dendrite), mosty (bridges) do protokołów zewnętrznych, szyfrowanie E2EE (Vodozemac/Megolm), oraz opcjonalny MLS stack. Każdy operator posiada własną instancję env-matrix, izolowaną kryptograficznie. Federacja między instancjami env-matrix różnych operatorów jest możliwa, ale domyślnie wyłączona (opt-in per-operator, wymagana wzajemna autoryzacja).

env-signal [N] — Typ workloadu mikroVM zapewniający kompatybilność z protokołem Signal. Env-signal nie jest natywnym klientem Signal, lecz workloadem kompatybilnościowym (compatibility workload) umożliwiającym komunikację z użytkownikami Signal. Env-signal działa wyłącznie jako bridge — wiadomości Signal są odbierane w env-signal, deszyfrowane w TEE, i przekazywane do env-matrix operatora. Env-signal jest modułem autonomicznym (nie certifiable core) i może być wyłączony per-operator. W kontekście suwerenności: Matrix jest rdzeniem komunikacyjnym SYLION, Signal jest jedynie kanałem kompatybilności.

env-browser [N] — Typ workloadu mikroVM zapewniający izolowane środowisko przeglądania WWW. Env-browser uruchamia zdalną instancję przeglądarki (Chromium w hardened configuration), izolowaną od pozostałych workloadów operatora. Strumień pikseli z env-browser jest przesyłany do terminala użytkownika. Env-browser zapewnia ochronę przed: atakami drive-by download, exploitami przeglądarkowym, fingerprinting i cookie tracking. Każda sesja env-browser jest efemeryczna — po zamknięciu stan jest niszczoney.

env-office [N] — Typ workloadu mikroVM zapewniający zdalne środowisko biurowe (edycja dokumentów, arkusze kalkulacyjne, prezentacje). Env-office uruchamia aplikacje biurowe w izolowanej mikroVM z dostępem wyłącznie do zaszyfrowanego storage operatora. Dokumenty nigdy nie opuszczają VPS Vault — edycja odbywa się zdalnie, terminal wyświetla jedynie strumień pikseli.

env-crm [N] — Typ workloadu mikroVM dedykowany systemowi CRM (Customer Relationship Management) operatora. Env-crm może hostować: instancję CRM (self-hosted) lub sesję zdalną do chmurowego CRM (via env-browser z ograniczonymi politykami egress). Dane CRM pozostają w Zone 3.

env-voice [N] — Typ workloadu mikroVM dedykowany usługom głosowym (VoIP, telekonferencje). Env-voice obejmuje: SIP gateway (opcjonalnie), WebRTC stack, kodeki audio/wideo, media relay. Env-voice operuje w media plane i jest izolowany od pozostałych workloadów — kompromitacja env-voice nie daje dostępu do env-matrix ani env-office.

FORTRESS [N] — Historyczna nazwa poprzedniej generacji platformy bezpiecznej komunikacji, z której ewoluował SYLION. FORTRESS stanowi punkt odniesienia architektonicznego i źródło lekcji wyciągniętych (lessons learned). W dokumentacji SYLION 3.0 odniesienia do FORTRESS są stosowane w kontekście: (a) ewolucji architektonicznej (co zmieniono i dlaczego), (b) migracji istniejących operatorów, (c) analizy porównawczej. Nazwa FORTRESS nie powinna być stosowana w komunikacji z nowymi operatorami — obowiązuje wyłącznie nazwa SYLION.

RSD (Reference Security Document) [N] — Centralny dokument referencyjny definiujący: (a) granicę między certifiable core a autonomous modules, (b) mapowanie wymagań bezpieczeństwa na komponenty, (c) matrycę zagrożeń i kontroli, (d) kryteria akceptacji dla audytów bezpieczeństwa. RSD jest utrzymywany przez Security Architecture Team, wersjonowany (RSD v3.0 odpowiada SYLION 3.0) i podlega formalnemu procesowi zmian (change control board).

Dark-Matrix [E] — Eksperymentalny tryb komunikacji Matrix, w którym metadane konwersacji (kto z kim, kiedy, częstotliwość) są dodatkowo chronione przez: (a) padding ruchu (constant-rate traffic), (b) routing onionowy wewnątrz platformy, (c) opóźnienia miksujące (mix delays). Dark-Matrix jest przeznaczony dla scenariuszy najwyższego poziomu zagrożenia, gdzie analiza metadanych (traffic analysis) stanowi istotne ryzyko. Status: eksperymentalny [E] — wymaga dodatkowych badań nad wpływem na latencję i UX.

Blind Broker [E] — Eksperymentalny wzorec architektoniczny, w którym Session Broker i media relay (SFU) nie posiadają dostępu do treści sesji — ani do tekstu wiadomości, ani do mediów. Blind Broker jest realizowany przez: (a) szyfrowanie end-to-end na poziomie klienta (env-matrix), (b) SFrame (RFC 9605) dla mediów, (c) ograniczenie SFU do forwarding zaszyfrowanych pakietów bez inspekcji. Status: eksperymentalny [E] — ze względu na ograniczenia SFrame opisane w RFC 9605 §7.2 (brak ochrony metadanych frame'ów, podatność na replay w specyficznych scenariuszach).

Hardware Heartbeat [N] — (Zdefiniowany w §5.3) — Termin wewnętrzny SYLION oznaczający ciągły, kryptograficznie weryfikowany sygnał z terminala. W materiałach marketingowych przedstawiany jako element „Zamka Biometrycznego” (zob. §5.9). Hardware Heartbeat jest unikatowym rozwiązaniem SYLION — nie ma bezpośredniego odpowiednika w standardach branżowych; najbliższe koncepcje to: Continuous Device Assurance (Google BeyondCorp) i Endpoint Compliance Verification (NIST SP 800-207).

5.9 Mapowanie terminów marketingowych na techniczne

Status: [R] Rekomendowany Odbiorca: Marketing, Sales, Product Management, Partner Relations, kadra zarządzająca Wpływ na baseline: Niski Powiązane rozdziały: 5.1, 5.2, 5.3, 7.3

Poniższe mapowanie ustanawia formalne powiązanie między terminami marketingowymi używanymi w komunikacji zewnętrznej a precyzyjnymi pojęciami technicznymi zdefiniowanymi w rozdziałach 5.1–5.8. Terminologia marketingowa jest dopuszczalna w materiałach promocyjnych, prezentacjach sprzedażowych i komunikacji z klientami, pod warunkiem że nie zniekształca ona rzeczywistych właściwości technicznych systemu. W dokumentacji technicznej, specyfikacjach i audytach muszą być stosowane wyłącznie terminy techniczne.

Termin marketingowy	Termin(y) techniczny(e)	Opis mapowania
„Cyfrowy Sejf”	VPS Vault / Zone 3 operator environment	Metafora podkreślająca, że dane operatora są przechowywane i przetwarzane wyłącznie w chronionym środowisku chmurowym (Zone 3), z szyfrowaniem at-rest, in-transit i in-use (Confidential Computing). „Sejf” oddaje koncepcję, że dane nigdy nie opuszczają chronionego środowiska w formie jawnej. Technicznie: VPS Vault = klastery mikroVM Firecracker + zaszyfrowany storage + SEV-SNP/TDX + CDR gateway w Zone 3. Ograniczenie metafory: „sejf” sugeruje statyczność, podczas gdy VPS Vault jest dynamicznym środowiskiem obliczeniowym.
„Amnezja Urządzenia”	No-persistent-data terminal policy	Metafora podkreślająca, że terminal (urządzenie końcowe) nie przechowuje żadnych danych biznesowych operatora — po zakończeniu sesji lub utracie urządzenia, na terminalu nie pozostają żadne informacje do odzyskania. Technicznie: polityka terminala wymuszająca brak trwałego storage dla danych sesji, brak cache'owania danych biznesowych, automatyczne czyszczenie pamięci po zakończeniu sesji, brak możliwości zrzutu ekranu (DRM/secure surface, jeśli wspierane przez OS). Ograniczenie: „amnezja” nie oznacza fizycznego zniszczenia danych na dysku urządzenia — odnosi się do warstwy aplikacyjnej SYLION.
„Zamek Biometryczny”	FIDO2 + Hardware Heartbeat	Metafora podkreślająca wieloskładnikowe uwierzytelnianie oparte na biometrii i sprzętowym tokenie. Technicznie: FIDO2 (klucz sprzętowy z weryfikacją biometryczną — odcisk palca lub rozpoznawanie twarzy) + Hardware Heartbeat (ciągła kryptograficzna atestacja urządzenia). „Zamek” oddaje koncepcję, że dostęp wymaga fizycznej obecności uprawnionego użytkownika z autoryzowanym urządzeniem. Ograniczenie: biometria w FIDO2 jest weryfikowana lokalnie na tokenie, nie jest przesyłana do serwera — metafora „zamka biometrycznego” nie powinna sugerować centralnego przechowywania danych biometrycznych.
„Tarcza”	G1 (Gateway 1)	Metafora podkreślająca rolę pierwszej warstwy bramy bezpieczeństwa jako „tarczy” chroniącej przed atakami zewnętrznymi. Technicznie: G1 = terminacja IPsec IKEv2, wstępne uwierzytelnienie, filtrowanie L3/L4, ochrona DDoS, w Zone 1 (DMZ). „Tarcza” oddaje defensywny, zewnętrzny charakter G1. Ograniczenie: G1 nie jest jedyną warstwą ochrony — metafora nie powinna sugerować, że „Tarcza” zapewnia kompletne bezpieczeństwo bez G2.
„Mózg”	G2 (Gateway 2)	Metafora podkreślająca rolę drugiej warstwy bramy bezpieczeństwa jako „inteligentnego” komponentu podejmującego decyzje autoryzacyjne. Technicznie: G2 = inspekcja L7, ABAC/PBAC enforcement, CDR processing, routing sesji, na granicy Zone 2/Zone 3. „Mózg” oddaje decyzyjną, kontekstową naturę G2 (w odróżnieniu od „Tarczy”, która filtruje mechanicznie). Ograniczenie: G2 nie jest jedynym komponentem „inteligentnym” — Policy Engine i Access Broker również podejmują decyzje.
„Spopielenie”	Cryptographic destroy + rebuild	Metafora podkreślająca proces nieodwracalnego zniszczenia danych operatora połączony z przebudową środowiska od podstaw. Technicznie: (a) cryptographic destroy — zniszczenie kluczy szyfrowania w HSM, co czyni zaszyfrowane dane nieodzyskiwalnymi (crypto-shredding), (b) secure erase storage, (c) zniszczenie wszystkich mikroVM i artefaktów, (d) rebuild — provisioning nowego, czystego środowiska z immutable images. „Spopielenie” oddaje nieodwracalność i kompletność procesu. Scenariusze użycia: offboarding operatora, reakcja na kompromitację, żądanie regulacyjne (prawo do usunięcia). Ograniczenie: logi audytu w Zone 4 podlegają retention policy i nie są „spopielane” — metafora dotyczy wyłącznie danych biznesowych operatora w Zone 3.

Zasady stosowania mapowania:

Materiały marketingowe mogą stosować terminy marketingowe, ale muszą posiadać techniczną recenzję (Technical Accuracy Review) przed publikacją.

Materiały kierowane do klientów technicznych (architekci, CISO) powinny stosować terminy techniczne z opcjonalnym odwołaniem do metafory marketingowej.

Materiały certyfikacyjne i audytowe muszą stosować wyłącznie terminologię techniczną.

W przypadku rozbieżności między materiałem marketingowym a dokumentacją techniczną, dokumentacja techniczna jest wiążąca.

Rozdział 6. Cytowanie, referencje i źródła

Status: [N] Normatywny Odbiorca: Wszyscy autorzy dokumentacji SYLION, architekci, badacze bezpieczeństwa, audytorzy Wpływ na baseline: Wysoki Powiązane rozdziały: 5.1, 7.1, 7.5, 7.6, 30.1, 87.1

Niniejszy rozdział ustanawia normatywne zasady cytowania, referencjonowania i klasyfikacji źródeł w dokumentacji systemu SYLION 3.0. Rzetelność cytowań jest fundamentem wiarygodności projektu — każde twierdzenie techniczne musi być weryfikowalne i odwołane do źródła o ustalonej wiarygodności. Zasady opisane w tym rozdziale muszą być przestrzegane we wszystkich dokumentach projektowych, specyfikacjach technicznych, raportach bezpieczeństwa i materiałach certyfikacyjnych.

6.1 Zasady cytowania wewnętrznych źródeł projektowych

Status: [N] Normatywny Odbiorca: Wszyscy autorzy dokumentacji SYLION Wpływ na baseline: Wysoki Powiązane rozdziały: 5.8, 6.2, 6.8, 7.1

Wewnętrzne źródła projektowe stanowią fundament dokumentacji SYLION 3.0 — obejmują analizy, specyfikacje i decyzje wypracowane w toku rozwoju platformy od FORTRESS do SYLION 3.0. Poniższe zasady zapewniają spójność, weryfikowalność i śledzenie pochodzenia twierdzeń w całej dokumentacji.

Format cytowania wewnętrznego. Każde odwołanie do źródła wewnętrznego musi zawierać: (a) identyfikator dokumentu, (b) wersję dokumentu, (c) datę wersji lub ostatniej modyfikacji, (d) numer sekcji lub strony, (e) klasyfikację poufności. Format kanoniczny:

[ID-DOKUMENTU vX.Y, §sekcja, YYYY-MM-DD, klasyfikacja]

Przykłady: - [RSD v3.0, §4.2.1, 2026-01-15, CONFIDENTIAL] - [FORTRESS-ANALYSIS v1.3, §7, 2024-06-20, INTERNAL] - [SYLION-SPEC v3.0, §12.4, 2026-03-01, CONFIDENTIAL]

Hierarchia dokumentów wewnętrznych. Dokumenty wewnętrzne SYLION są uporządkowane hierarchicznie pod względem autorytetu:

RSD (Reference Security Document) — najwyższy autorytet wewnętrzny; definiuje granicę certifiable core, mapowanie wymagań i kryteria bezpieczeństwa. Cytowanie RSD ma pierwszeństwo przed innymi dokumentami wewnętrznymi w przypadku konfliktu.

SYLION Specification v3.0 — specyfikacja architektoniczna i funkcjonalna platformy; definiuje „co” i „jak” systemu. Specyfikacja jest normatywna dla implementacji.

SYLION Specification v2.1 / v2.0 — poprzednie wersje specyfikacji; cytowane wyłącznie w kontekście ewolucji architektury i uzasadnienia zmian (decision log).

FORTRESS Analysis — analiza platformy FORTRESS; cytowana w kontekście lekcji wyciągniętych, decyzji migracyjnych i analizy porównawczej.

Comparison Documents — dokumenty porównawcze (SYLION vs. konkurencja, SYLION vs. FORTRESS, analiza alternatyw technologicznych); cytowane w kontekście uzasadnienia wyborów architektonicznych.

Internal Memos, Meeting Notes, ADR (Architecture Decision Records) — źródła pomocnicze; cytowane wyłącznie jako kontekst historyczny, nigdy jako jedyny dowód twierdzenia normatywnego.

Zasady wersjonowania. Cytowania muszą odwoływać się do konkretnej wersji dokumentu, nie do „najnowszej” (latest). Jeśli dokument źródłowy został zaktualizowany po napisaniu cytującego tekstu, autor musi zweryfikować, czy cytowane twierdzenie nadal obowiązuje w nowej wersji. Rozbieżności muszą być odnotowane w Rejestrze Odchyłań.

Dokumenty archiwalne. Dokumenty FORTRESS i wersje SYLION <3.0 muszą być oznaczone tagiem [ARCHIVAL] w cytowaniu. Twierdzenia oparte wyłącznie na źródłach archiwalnych muszą być weryfikowane pod kątem aktualności w kontekście SYLION 3.0.

Poufność. Cytowania dokumentów o klasyfikacji wyższej niż dokument cytujący są zabronione — np. dokument INTERNAL nie może cytować dokumentu RESTRICTED w sposób ujawniający treść zastrzeżoną. Dopuszczalne jest odwołanie do identyfikatora dokumentu bez cytowania treści.

6.2 Zasady cytowania źródeł zewnętrznych

Status: [N] Normatywny Odbiorca: Wszyscy autorzy dokumentacji SYLION Wpływ na baseline: Wysoki Powiązane rozdziały: 6.1, 6.3, 6.4

Źródła zewnętrzne obejmują: standardy, normy, RFC, publikacje akademickie, dokumentację vendorów, raporty audytowe, bazy podatności (CVE) oraz analizy niezależnych badaczy. Cytowanie źródeł zewnętrznych podlega rygorystycznym zasadom zapewniającym wiarygodność i weryfikowalność.

Format cytowania zewnętrznego. Każde odwołanie do źródła zewnętrznego musi zawierać: (a) identyfikator lub tytuł źródła, (b) autora/organizację, (c) datę publikacji, (d) numer sekcji lub strony (jeśli dotyczy), (e) URL lub DOI (jeśli dostępne), (f) datę ostatniego dostępu (dla źródeł online). Format kanoniczny:

[Autor/Organizacja, "Tytuł", identyfikator, data, §sekcja, URL, dostęp: YYYY-MM-DD]

Przykłady: - [NIST, "Zero Trust Architecture", SP 800-207, 2020-08, §3.1, <https://doi.org/10.6028/NIST.SP.800-207>] - [Kaufman et al., "Internet Key Exchange Protocol Version 2 (IKEv2)", RFC 7296, 2014-10, §2.1, <https://www.rfc-editor.org/rfc/rfc7296>] - [Willers et al., "Battering RAM", Proc. IEEE S&P, 2025, §IV, <https://doi.org/...>]

Wymagania dotyczące źródeł akademickich. Publikacje akademickie cytowane w dokumentacji SYLION muszą spełniać co najmniej jeden z warunków: (a) opublikowane w recenzowanym czasopiśmie lub konferencji (IEEE S&P, USENIX Security, ACM CCS, NDSS, CRYPTO, EUROCRYPT), (b) opublikowane jako preprint na eprint.iacr.org z późniejszą akceptacją na konferencję, (c) opublikowane przez uznaną instytucję badawczą (NIST, ENISA, BSI). Preprints bez recenzji mogą być cytowane wyłącznie z oznaczeniem [PREPRINT — NOT PEER-REVIEWED].

Wymagania dotyczące RFC. RFC cytowane w SYLION muszą być identyfikowane pełnym numerem i statusem (Standards Track, Informational, Experimental, Best Current Practice). RFC o statusie Experimental lub Informational mogą uzasadniać decyzje architektoniczne, ale nie mogą stanowić jedynej podstawy twierdzeń normatywnych.

Wymagania dotyczące dokumentacji vendorów. Dokumentacja techniczna vendorów (AMD, Intel, AWS, Firecracker, Matrix.org) jest dopuszczalnym źródłem dla: (a) specyfikacji technicznych produktów stosowanych w SYLION, (b) informacji o znanych ograniczeniach i podatnościach, (c) wytycznych konfiguracyjnych. Dokumentacja vendorów nie jest wystarczającym źródłem dla twierdzeń o bezpieczeństwie — twierdzenia dotyczące bezpieczeństwa muszą być potwierdzone niezależnymi badaniami lub audytami.

Wymagania dotyczące CVE. Odwołania do CVE muszą zawierać: numer CVE, datę publikacji, scoring CVSS, status (confirmed/disputed/rejected), oraz dostawcę (vendor advisory). CVE stanowią dopuszczalne źródło dla: modelowania zagrożeń, uzasadnienia decyzji architektonicznych (np. rezygnacja z komponentu z historią krytycznych CVE), planowania łatania. CVE nie mogą być jedynym dowodem na niebezpieczeństwo technologii — wymagana jest analiza kontekstowa (czy CVE dotyczy konfiguracji stosowanej w SYLION).

Źródła niedopuszczalne. Następujące typy źródeł nie mogą stanowić podstawy twierdzeń normatywnych: (a) posty na blogach bez recenzji, (b) wpisy w mediach społecznościowych, (c) materiały marketingowe vendorów (broшуry, case studies), (d) artykuły prasowe bez odesłania do pierwotnego źródła technicznego, (e) materiały niepublikowane (leaks, nieautoryzowane ujawnienia). Źródła te mogą być cytowane wyłącznie jako kontekst informacyjny z oznaczeniem [INFORMATIONAL — LOW CONFIDENCE].

6.3 Typy źródeł: normy, RFC, dokumentacja, audyty, badania, CVE

Status: [N] Normatywny Odbiorca: Wszyscy autorzy dokumentacji SYLION Wpływ na baseline: Średni Powiązane rozdziały: 6.1, 6.2, 6.4

Klasyfikacja źródeł według typu jest kluczowa dla poprawnej oceny wiarygodności i zakresu stosowania każdego cytowania. Poniższa taksonomia definiuje sześć kanonicznych typów źródeł stosowanych w dokumentacji SYLION 3.0.

Typ 1: Normy i standardy (Standards). Obejmuje: NIST SP, FIPS, ISO/IEC, CC, DISA STIG, CNSA. Charakterystyka: opracowane przez uznane organizacje normalizacyjne, poddane publicznej konsultacji, formalnie opublikowane, wersjonowane, stabilne. Autorytet: najwyższy — normy stanowią „prawo” w kontekście zgodności. W SYLION normy są cytowane jako: (a) wymagania, które system musi spełnić (compliance mapping), (b) źródło wymagań bezpieczeństwa mapowanych na certifiable core, (c) referencyjna architektura (np. NIST SP 800-207 dla Zero Trust). Cykl życia: normy są rzadko wycofywane — nowe wersje zastępują stare. Cytowanie musi odwoływać się do konkretnej wersji normy. Przykład: NIST SP 800-207 (08/2020) definiuje architekturę Zero Trust jako fundament projektowy SYLION.

Typ 2: RFC (Request for Comments). Obejmuje: dokumenty IETF definiujące protokoły internetowe (RFC 7296 — IKEv2, RFC 9370 — PQC IPsec, RFC 9605 — SFrame). Charakterystyka: poddane procesowi recenzji IETF (IESG review), opublikowane z numerem i statusem, niemodyfikowalne po publikacji (errata i updates jako osobne dokumenty). Autorytet: wysoki — RFC Standards Track są de facto obowiązujące dla protokołów internetowych. W SYLION RFC są cytowane jako: (a) specyfikacja protokołów stosowanych w platformie (IPsec, IKEv2, TLS, Matrix), (b) źródło znanych ograniczeń i wymogów interoperacyjności, (c) uzasadnienie wyborów technologicznych. Uwaga: RFC o statusie Experimental lub Informational mają niższy autorytet niż Standards Track.

Typ 3: Dokumentacja techniczna vendorów (Vendor Documentation). Obejmuje: AMD SEV-SNP Firmware ABI Specification, Intel TDX Module Specification, AWS Firecracker Design Document, Matrix Specification, Signal Protocol Technical Documentation. Charakterystyka: opracowana i publikowana przez dostawcę technologii, aktualizowana w cyklu release produktu, nie poddana zewnętrznej recenzji. Autorytet: średni — dokumentacja vendora jest autorytatywna dla specyfikacji produktu, ale nie dla twierdzeń o bezpieczeństwie (vendor nie jest obiektywnym źródłem oceny własnego produktu). W SYLION dokumentacja

vendorów jest cytowana jako: (a) specyfikacja techniczna komponentów, (b) informacja o konfiguracjach, API i ograniczeniach, (c) changelogi i release notes. Wymaganie: twierdzenia bezpieczeństwa oparte na dokumentacji vendora muszą być potwierdzone niezależnym źródłem (Typ 4 lub Typ 5).

Typ 4: Audyty i raporty bezpieczeństwa (Security Audits). Obejmuje: raporty penetration testingów, audyty kodu (np. NCC Group, Trail of Bits, Cure53), raporty SOC 2, certyfikaty CC, FedRAMP authorization packages. Charakterystyka: opracowane przez niezależne podmioty, metodologia zdefiniowana (OWASP, PTES, CC CEM), wyniki datowane i ograniczone czasowo (audit recency). Autorytet: wysoki — niezależne audyty stanowią najsilniejszy dowód bezpieczeństwa po standardach. W SYLION audyty są cytowane jako: (a) potwierdzenie skuteczności kontroli, (b) identyfikacja podatności i plan remediacji, (c) materiał certyfikacyjny. Ograniczenie: audyt jest snapshot'em — odzwierciedla stan systemu w momencie przeprowadzenia. Audyty starsze niż 12 miesięcy muszą być oznaczone [AGING — REVALIDATION RECOMMENDED].

Typ 5: Badania akademickie (Academic Research). Obejmuje: publikacje konferencyjne (IEEE S&P, USENIX, ACM CCS, NDSS, CRYPTO), artykuły w recenzowanych czasopiśmie, raporty instytucji badawczych. Charakterystyka: poddane procesowi peer-review, powtarzalne (reproducibility), cytowalne (DOI). Autorytet: wysoki — badania akademickie stanowią fundament wiedzy o zagrożeniach i mechanizmach ochrony. W SYLION badania akademickie są cytowane jako: (a) dowód na istnienie zagrożeń (np. „Battering RAM” — ataki na SEV-SNP), (b) analiza skuteczności mechanizmów ochrony, (c) propozycje nowych rozwiązań (np. SFrame, MLS). Ograniczenie: badania proof-of-concept nie oznaczają praktycznej exploitowalności — wymagana jest analiza kontekstowa.

Typ 6: Bazy podatności i intelligence (Vulnerability Databases). Obejmuje: NVD/CVE, CISA KEV, vendor security advisories. Charakterystyka: ustrukturyzowane, maszynowo odczytywalne, aktualizowane ciągle. Autorytet: średni-wysoki — CVE potwierdzone przez vendora mają wysoki autorytet; CVE disputed lub bez vendora advisory mają niższy autorytet. W SYLION CVE są cytowane jako: (a) dowód w modelowaniu zagrożeń, (b) uzasadnienie decyzji architektonicznych, (c) input do procesu patch management. Ograniczenie: scoring CVSS jest generyczny — wymagana jest kontekstualizacja (CVSS-BT lub VEX) dla środowiska SYLION.

6.4 Hierarchia wiarygodności źródeł

Status: [N] Normatywny Odbiorca: Wszyscy autorzy dokumentacji SYLION Wpływ na baseline: Wysoki Powiązane rozdziały: 6.1, 6.2, 6.3, 6.5

Hierarchia wiarygodności źródeł definiuje priorytet i wagę różnych typów źródeł w procesie podejmowania decyzji architektonicznych, walidacji twierdzeń bezpieczeństwa i rozstrzygania konfliktów między źródłami. Przestrzeganie hierarchii jest obowiązkowe dla wszystkich autorów dokumentacji SYLION 3.0.

Tier 1 — Źródła autorytatywne (Authoritative Sources). Najwyższy poziom wiarygodności. Twierdzenia oparte wyłącznie na źródłach Tier 1 mogą mieć status normatywny [N] bez dodatkowej walidacji.

Obejmuje: - Standardy NIST: SP 800-207, SP 800-63, SP 800-53, SP 800-190, FIPS 140-3, FIPS 203/204/205 - Standardy ISO/IEC: 15408 (CC), 27001, 27017, 27018, 19790 (moduły kryptograficzne) - RFC Standards Track: RFC 7296 (IKEv2), RFC 4303 (ESP), RFC 9370 (PQC IPsec), RFC 8446 (TLS 1.3) - Publikacje CNSA 2.0 (NSA/CISA) - DISA STIG (po formalnej publikacji)

Uzasadnienie: źródła Tier 1 przechodzą rygorystyczny proces recenzji, konsultacji publicznej i formalnej publikacji. Są uznawane przez organy certyfikacyjne (NIAP, FedRAMP, BSI).

Tier 2 — Źródła wysokiej wiarygodności (High-Confidence Sources). Twierdzenia oparte na źródłach Tier 2 mogą mieć status rekomendowany [R]. Status normatywny [N] wymaga potwierdzenia źródłem Tier 1 lub niezależnej walidacji.

Obejmuje: - Recenzowane publikacje akademickie (top-tier venues: IEEE S&P, USENIX Security, ACM CCS, NDSS, CRYPTO, EUROCRYPT) - Whitepapers bezpieczeństwa vendorów wsparte niezależnym audytem (np. Firecracker Security Model z audytem Trail of Bits) - Raporty niezależnych firm audytowych (NCC Group, Trail of Bits, Cure53, Quarkslab) - RFC Informational/Experimental (z odpowiednim oznaczeniem statusu)

Uzasadnienie: źródła Tier 2 przechodzą recenzję, ale mają węższy zakres walidacji niż standardy. Badania akademickie mogą prezentować wyniki proof-of-concept bez pełnej walidacji produkcyjnej.

Tier 3 — Źródła średniej wiarygodności (Medium-Confidence Sources). Twierdzenia oparte na źródłach Tier 3 mogą mieć status warunkowy [O] lub eksperymentalny [E]. Nie mogą stanowić jedynej podstawy twierdzenia normatywnego.

Obejmuje: - Bazy CVE/NVD (potwierdzone przez vendora) - Niezależne audyty bezpieczeństwa (firmy spoza Tier 2) - Dokumentacja techniczna vendorów (AMD, Intel, AWS, Matrix.org) bez niezależnej walidacji - CISA advisories, CERT bulletins - Analizy operacyjne law enforcement (EncroChat, Sky ECC, ANOM — na podstawie dokumentów sądowych)

Uzasadnienie: źródła Tier 3 są wiarygodne, ale mogą być: (a) nieobiektywne (dokumentacja vendora), (b) niekompletne (CVE bez pełnej analizy), (c) ograniczone czasowo (audyt jako snapshot).

Tier 4 — Źródła niskiej wiarygodności (Low-Confidence Sources). Twierdzenia oparte wyłącznie na źródłach Tier 4 muszą być oznaczone [LOW CONFIDENCE — REQUIRES VALIDATION]. Nie mogą mieć statusu wyższego niż informacyjny [I].

Obejmuje: - Materiały marketingowe vendorów (brozury, case studies, strony produktowe) - Wpisy na blogach (nawet technicznych, np. inżynierskich blogów Google, Cloudflare) - Artykuły prasowe i dziennikarstwo śledcze (bez odesłania do dokumentów źródłowych) - Prezentacje konferencyjne bez towarzyszącej publikacji recenzowanej - Internet Drafts (IETF) przed akceptacją jako RFC

Uzasadnienie: źródła Tier 4 nie przechodzą formalnej recenzji i mogą zawierać uproszczenia, błędy lub celowe przekłamania. Ich wartość jest kontekstowa — mogą sygnalizować kierunek badań lub problemy, ale wymagają walidacji ze źródeł wyższego tieru.

Rozstrzyganie konfliktów. W przypadku sprzecznych informacji między źródłami: (a) źródło wyższego tieru ma pierwszeństwo, (b) w ramach tego samego tieru — nowsze źródło ma pierwszeństwo (z wyjątkiem stabilnych standardów), (c) jeśli konflikt dotyczy bezpieczeństwa — obowiązuje zasada ostrożności (przyjmujemy gorszy scenariusz), (d) każdy rozstrzygnięty konflikt musi być odnotowany w Rejestrze Decyzji (§6.8).

6.5 Oznaczanie twierdzeń potwierdzonych, warunkowych i eksperymentalnych

Status: [N] Normatywny Odbiorca: Wszyscy autorzy dokumentacji SYLION Wpływ na baseline: Wysoki Powiązane rozdziały: 6.3, 6.4, 7.6

Każde twierdzenie techniczne i bezpieczeństwa w dokumentacji SYLION 3.0 musi być oznaczone statusem odzwierciedlającym poziom pewności i walidacji. System oznaczeń zapewnia transparentność — czytelnik natychmiast wie, czy dane twierdzenie jest faktem potwierdzonym, warunkową rekomendacją czy hipotezą

wymagającą walidacji.

Twierdzenia potwierdzone (Confirmed Claims) — oznaczenie [CONFIRMED]. Twierdzenie oparte na źródłach Tier 1 lub Tier 2, zwalidowane w kontekście architektury SYLION 3.0. Twierdzenia potwierdzone mogą stanowić podstawę decyzji normatywnych i być cytowane w materiałach certyfikacyjnych. Wymaganie: twierdzenie potwierdzone musi posiadać co najmniej jedno źródło Tier 1 lub Tier 2 oraz musi być aktualne (źródło nie starsze niż 3 lata dla standardów, 2 lata dla badań, 1 rok dla audytów). Język dokumentacyjny: „jest”, „zapewnia”, „wymaga”, „musi”. Przykład: „IPsec IKEv2 zapewnia zgodność z CNSA 2.0 timeline [CONFIRMED] [CNSA 2.0, NSA, 2022-09]”.

Twierdzenia warunkowe (Conditional Claims) — oznaczenie [CONDITIONAL]. Twierdzenie, którego prawdziwość zależy od spełnienia określonych warunków (konfiguracja, wersja, kontekst wdrożenia). Twierdzenia warunkowe mogą stanowić podstawę rekomendacji [R], ale nie wymagań normatywnych [N] bez specyfikacji warunków. Wymaganie: twierdzenie warunkowe musi jawnie wymieniać warunki, od których zależy jego prawdziwość. Język dokumentacyjny: „pod warunkiem, że”, „w konfiguracji”, „jeśli”, „powinien”. Przykład: „AMD SEV-SNP chroni dane w pamięci przed dostępem hypervisora, pod warunkiem że firmware ASP jest w wersji ≥1.55.18 i atestacja zdalna jest włączona [CONDITIONAL] [AMD SEV-SNP ABI Spec v1.55]”.

Twierdzenia eksperymentalne (Experimental Claims) — oznaczenie [EXPERIMENTAL]. Twierdzenie oparte na wstępnych badaniach, prototypach lub analizie teoretycznej, które nie zostało jeszcze w pełni zwalidowane w kontekście SYLION 3.0. Twierdzenia eksperymentalne mogą stanowić podstawę statusu [E] (eksperymentalny) i kierunku badawczego, ale nie mogą wpływać na decyzje normatywne ani certyfikacyjne. Wymaganie: twierdzenie eksperymentalne musi być: (a) jawnie oznaczone, (b) opatrzone planem walidacji (co musi być zwalidowane i do kiedy), (c) powiązane z osobą odpowiedzialną za walidację. Język dokumentacyjny: „w fazie badawczej”, „wymaga walidacji”, „wstępne wyniki wskazują”, „hipotetycznie”. Przykład: „Blind Broker z SFrame może zapewnić ochronę treści mediów przed SFU, jednak ograniczenia opisane w RFC 9605 §7.2 wymagają dalszych badań [EXPERIMENTAL] [plan walidacji: Q3 2026, odpowiedzialny: Security Research Team]”.

Twierdzenia odrzucone (Rejected Claims) — oznaczenie [REJECTED]. Twierdzenie, które było rozważane w procesie projektowym, ale zostało odrzucone na podstawie analizy. Twierdzenia odrzucone są dokumentowane w celu zachowania institutional memory i zapobieżenia powracaniu do już rozstrzygniętych kwestii (anti-pattern: zombie decisions). Wymaganie: twierdzenie odrzucone musi być opatrzone: (a) uzasadnieniem odrzucenia, (b) źródłem(ami) uzasadniającymi odrzucenie, (c) datą decyzji. Przykład: „WireGuard jako protokół tunelowania — odrzucony ze względu na brak zgodności z CNSA 2.0 (brak wsparcia PQC w protokole, brak FIPS 140-3 validated module) [REJECTED] [decyzja: 2025-11-15, źródło: CNSA 2.0 timeline, §3.2]”.

Twierdzenia przestarzałe (Deprecated Claims) — oznaczenie [DEPRECATED]. Twierdzenie, które było potwierdzone w poprzedniej wersji dokumentacji, ale zostało zastąpione nowym twierdzeniem (np. ze względu na zmianę specyfikacji, nowe badania, aktualizację standardu). Twierdzenia przestarzałe są zachowywane w historii dokumentacji, ale muszą być oznaczone jako nieaktualne. Wymaganie: twierdzenie przestarzałe musi wskazywać nowe, obowiązujące twierdzenie (replacement).

Tabela podsumowująca:

Oznaczenie	Dopuszczalny status rozdziału	Min. tier źródła	Język normatywny
[CONFIRMED]	[N], [R], [O]	Tier 1 lub Tier 2	„musi”, „jest”, „zapewnia”
[CONDITIONAL]	[R], [O]	Tier 2 lub Tier 3	„powinien”, „pod warunkiem”
[EXPERIMENTAL]	[E]	Tier 3 lub Tier 4	„wymaga walidacji”, „wstępnie”
[REJECTED]	n/d (archiwalne)	dowolny	„odrzucono”, „nie stosować”
[DEPRECATED]	n/d (archiwalne)	n/d	„zastąpiono przez”

6.6 Bibliografia główna

Status: [N] Normatywny Odbiorca: Wszyscy uczestnicy projektu Wpływ na baseline: Wysoki Powiązane rozdziały: 6.1, 6.4, 6.7, 6.8

Bibliografia główna obejmuje źródła fundamentalne dla architektury, bezpieczeństwa i zgodności SYLION 3.0. Każde źródło w bibliografii głównej jest cytowane w co najmniej trzech rozdziałach Księgi i stanowi podstawę decyzji architektonicznych lub wymagań bezpieczeństwa. Źródła są uporządkowane tematycznie i opatrzone identyfikatorem referencyjnym do stosowania w cytowaniach.

Architektura Zero Trust:

[ZTA-NIST] NIST, “Zero Trust Architecture”, Special Publication 800-207, sierpień 2020. DOI: 10.6028/NIST.SP.800-207. — Fundamentalny dokument definiujący architekturę Zero Trust jako model bezpieczeństwa sieci. Stanowi referencję dla: modelu Split Gateway, ciągłej weryfikacji sesji, polityk ABAC/PBAC, oraz eliminacji implicit trust. SYLION implementuje wariant ZTA z PEP (Policy Enforcement Point) na G1/G2 i PDP (Policy Decision Point) w Policy Engine.

[IDENTITY-NIST] NIST, “Digital Identity Guidelines”, Special Publication 800-63 (Rev. 4 draft), 2024. — Definiuje wymagania dla Identity Assurance Level (IAL), Authenticator Assurance Level (AAL) i Federation Assurance Level (FAL). SYLION implementuje AAL3 (hardware-bound authenticator — FIDO2) jako minimum dla tieru STATE/SOVEREIGN.

Kryptografia i protokoły:

[IKEv2-RFC] Kaufman, C., Hoffman, P., Nir, Y., Eronen, P., Kivinen, T., “Internet Key Exchange Protocol Version 2 (IKEv2)”, RFC 7296, październik 2014. — Specyfikacja protokołu IKEv2, podstawy negocjacji kluczy IPsec w SYLION. IKEv2 jest preferowany nad IKEv1 ze względu na: prostszą maszynę stanów, wbudowane wsparcie EAP, NAT traversal, MOBIKE.

[PQC-IPSEC] Tjhai, C., Tomlinson, M., Bartlett, G., Mayberry, S., Liu, D., “Multiple Key Exchanges in the Internet Key Exchange Protocol Version 2 (IKEv2)”, RFC 9370, maj 2023. — Definiuje mechanizm wielokrotnej wymiany kluczy w IKEv2, umożliwiającą hybrydowe PQC (klasyczny + postquantum). Kluczowe dla realizacji CNSA 2.0 timeline.

[CNSA-2.0] NSA/CISA, “Commercial National Security Algorithm Suite 2.0”, wrzesień 2022 (aktualizacje 2023–2024). — Definiuje zestaw algorytmów i harmonogram przejścia na PQC dla National Security Systems. Bezpośrednia podstawa decyzji o wyborze IPsec IKEv2 zamiast WireGuard (zob. §6.8).

[FIPS-203] NIST, “Module-Lattice-Based Key-Encapsulation Mechanism Standard”, FIPS 203, sierpień 2024. — Standard ML-KEM (dawniej CRYSTALS-Kyber), algorytm PQC wymiany kluczy stosowany w SYLION.

[FIPS-204] NIST, "Module-Lattice-Based Digital Signature Standard", FIPS 204, sierpień 2024. — Standard ML-DSA (dawniej CRYSTALS-Dilithium), algorytm PQC podpisu cyfrowego.

[FIPS-205] NIST, "Stateless Hash-Based Digital Signature Standard", FIPS 205, sierpień 2024. — Standard SLH-DSA (dawniej SPHINCS+), backup algorytm PQC podpisu cyfrowego.

Confidential Computing:

[SEV-SNP] AMD, "SEV Secure Nested Paging Firmware ABI Specification", Rev. 1.55, 2023. — Specyfikacja interfejsu firmware AMD SEV-SNP. Źródło wymagań atestacji zdalnej i konfiguracji izolacji pamięci VM.

[FIRECRACKER] AWS, "Firecracker — Lightweight Virtualization for Serverless Computing", NSDI '20, 2020. — Opis architektury hypervisora Firecracker i modelu bezpieczeństwa (jailer, seccomp, device model). Basis dla decyzji o adopcji Firecracker jako hypervisora mikroVM.

Komunikacja:

[MATRIX-SPEC] The Matrix.org Foundation, "Matrix Specification", v.1.10+, 2024. — Specyfikacja protokołu Matrix, w tym: Client-Server API, Server-Server Federation, End-to-End Encryption (Megolm/Vodozemac). Basis decyzji o wyborze Matrix jako core communication protocol (suwerenność, federacja, E2EE).

[SIGNAL-SPEC] Signal Foundation, "Signal Protocol: Technical Documentation", 2023. — Specyfikacja protokołu Signal (Double Ratchet, X3DH, Sealed Sender). Cytowana w kontekście: (a) kompatybilności env-signal, (b) porównania z Matrix E2EE, (c) analizy ograniczeń centralizacji Signal.

[SFRAME] Omara, E., Uberti, J., Oyman, A., "Secure Frame (SFrame): End-to-End Media Encryption", RFC 9605, sierpień 2024. — Specyfikacja SFrame dla szyfrowania mediów E2E w kontekście SFU. Cytowana w analizie Blind Broker (§5.8) i znanych ograniczeń (§7.2 RFC 9605).

6.7 Bibliografia pomocnicza

Status: [R] Rekomendowany Odbiorca: Architekci bezpieczeństwa, badacze, analitycy zagrożeń Wpływ na baseline: Średni Powiązane rozdziały: 6.6, 6.8, 30.1

Bibliografia pomocnicza obejmuje źródła stanowiące kontekst rynkowy, threat intelligence i analizę przypadków (case studies) istotnych dla modelu zagrożeń SYLION 3.0. Źródła te nie stanowią bezpośredniej podstawy wymagań architektonicznych, ale informują o krajobrazie zagrożeń, precedensach regulacyjnych i lekcjach wyciągniętych z kompromitacji konkurencyjnych platform.

Analizy kompromitacji platform bezpiecznej komunikacji:

[ENCROCHAT] Europol / French JIRS / Dutch Police, "EncroChat Takedown — Operation Venetic/Lemont", 2020. Dokumenty sądowe i komunikaty Europol. — EncroChat była zaszyfrowaną platformą komunikacyjną skompromitowaną przez francuskojęzyczną żandarmerię poprzez implant na poziomie firmware'u. Lekcje dla SYLION: (a) firmware terminala musi być weryfikowalny (Secure Boot + Remote Attestation), (b) scentralizowane OTA updates stanowią single point of compromise, (c) szyfrowanie E2EE jest bezwartościowe, jeśli endpoint jest skompromitowany. Tier źródła: 3 (dokumenty sądowe, komunikaty law enforcement).

[SKY-ECC] Europol / Belgian Federal Police, "Sky ECC Disruption — Operation Argus", 2021. — Platforma Sky ECC została skompromitowana przez belgijską policję, prawdopodobnie poprzez dystrybuowanie zmodyfikowanej aplikacji klienckiej. Lekcje dla SYLION: (a) integralność kanału dystrybucji aplikacji jest krytyczna, (b) model thin client (SYLION) jest odporniejszy niż model fat client (Sky ECC) — klient SYLION nie posiada danych do exfiltracji, (c) konieczność SBOM i weryfikacji łańcucha dostaw.

[ANOM] FBI / AFP, "ANOM — Operation Trojan Shield / Ironside", 2021. — ANOM była zaszyfrowaną platformą komunikacyjną potajemnie stworzoną i zarządzaną przez FBI. Każda wiadomość była kopiowana do serwerów FBI. Lekcje dla SYLION: (a) transparentność kodu i audyty zewnętrzne są warunkiem koniecznym zaufania, (b) model open-source (Matrix protocol) zapewnia weryfikowalność, (c) suwerenność operatora (własne klucze, własna instancja) eliminuje ryzyko backdoora w infrastrukturze centralnej.

[GHOST] AFP / Europol, "Ghost Encrypted Platform Takedown — Operation Kraken", 2024. — Ghost była kolejną zaszyfrowaną platformą skompromitowaną przez koalicję agencji. Lekcje dla SYLION: (a) jednoosobowe zarządzanie infrastrukturą (single administrator) stanowi katastrofalne ryzyko operacyjne, (b) brak dual authorization umożliwia insider threat, (c) konieczność formalnego modelu zarządzania dostępem privileged.

[MATRIX-PL] Europol, "MATRIX Encrypted Messaging Takedown", grudzień 2024. — Platforma o nazwie MATRIX (bez związku z protokołem Matrix.org) została skompromitowana przez holendersko-francuską operację. Lekcje dla SYLION: (a) nazwa „MATRIX” w kontekście skompromitowanej platformy wymaga jasnego rozróżnienia od protokołu Matrix.org, (b) serwery zlokalizowane w jednej jurysdykcji są podatne na przejęcie sądowe — architektura wielojurysdykcyjna jest rekomendowana dla tieru STATE.

[BULUT] Türk Emniyet Genel Müdürlüğü / Europol, "Operation BULUT — Bcrypt Platform", 2025. — Skompromitowanie platformy Bcrypt w Turcji. Lekcje: potwierdza trend operacyjny — platformy bez formalnych audytów i certyfikacji są systematycznie eliminowane przez organy ścigania.

Badania akademickie — ataki i obrona:

[BATTERING-RAM] Willers, L., et al., "Battering RAM: Rowhammer Attacks on AMD SEV", KU Leuven / CISP, prezentowane na IEEE S&P 2025. — Badanie demonstrujące atak Rowhammer na maszyny wirtualne chronione przez AMD SEV-SNP, umożliwiające ekstrakcję kluczy kryptograficznych z pamięci VM sąsiedniej. Implikacje dla SYLION: SEV-SNP stanowi warstwę defense-in-depth, nie absolutną granicę bezpieczeństwa. Mitigacje: (a) ECC memory (obowiązkowe), (b) ograniczenie co-tenancy na poziomie fizycznym dla tieru STATE, (c) monitoring anomalii pamięciowych. Tier źródła: 2 (top-tier academic venue).

[COUNTERSEV] Schlüter, M., et al., "CounterSEVveillance: Performance-Counter Attacks on AMD SEV-SNP", RWTH Aachen / University of Lübeck, 2024. — Badanie demonstrujące atak side-channel na SEV-SNP z wykorzystaniem hardware performance counters. Potwierdzenie, że SEV-SNP nie eliminuje wszystkich kanałów bocznych. Mitigacje: ograniczenie dostępu do PMC (performance monitoring counters) na nodach SEV-SNP.

Referencje komercyjne:

[HYPORI] Hypori Inc., "Hypori Halo — FedRAMP Authorized Virtual Device Infrastructure", FedRAMP Marketplace, 2023. — Platforma VDI z autoryzacją FedRAMP; referencyjna jako dowód wykonalności modelu thin client w sektorze rządowym USA. Cytowana w kontekście porównawczym (SYLION vs. Hypori architektura).

6.8 Rejestr decyzji opartych na źródłach

Status: [N] Normatywny Odbiorca: Architecture Board, architekci, Security Team, kadra zarządzająca Wpływ na baseline: Krytyczny Powiązane rozdziały: 6.1–6.7, 24.1, 25.1, 30.1

Rejestr decyzji opartych na źródłach (Source-Based Decision Register) dokumentuje kluczowe decyzje architektoniczne i bezpieczeństwa SYLION 3.0, które zostały podjęte na podstawie konkretnych, identyfikowalnych źródeł. Rejestr zapewnia: (a) śledzenie uzasadnień (traceability), (b) możliwość rewizji decyzji w przypadku zmiany kontekstu, (c) transparentność dla audytorów i certyfikatorów, (d) institutional memory — zapobieganie powracaniu do już rozstrzygniętych kwestii.

Każdy wpis w rejestrze ma format: identyfikator decyzji, data, opis, uzasadnienie z cytowaniem źródeł, status, warunki rewizji.

DEC-001: Wybór IPsec IKEv2 zamiast WireGuard jako protokołu tunelowania

Data decyzji: 2025-11-15

Status: [CONFIRMED] — obowiązujący

Opis: SYLION stosuje IPsec IKEv2 (RFC 7296) jako jedyny protokół tunelowania między terminalem a infrastrukturą platformy. WireGuard został rozważony i odrzucony.

Uzasadnienie:

CNSA 2.0 compliance [CNSA-2.0]: harmonogram CNSA 2.0 wymaga przejścia na kryptografię PQC do 2030/2033. IPsec IKEv2 posiada standaryzowany mechanizm wielokrotnej wymiany kluczy umożliwiający hybrydowe PQC [PQC-IPSEC, RFC 9370]. WireGuard oparty jest na Noise Protocol Framework z kryptografią Curve25519 i ChaCha20-Poly1305 — nie posiada standaryzowanego mechanizmu PQC ani ścieżki FIPS walidacji.

FIPS 140-3 validation [FIPS-140-3]: dostępne są FIPS-walidowane implementacje IPsec (np. Red Hat Libreswan, StrongSwan z modułem FIPS). WireGuard nie posiada FIPS 140-3 walidowanego modułu kryptograficznego na dzień podjęcia decyzji.

CSfC compatibility [CSfC-CP]: CSfC Mobile Access Capability Package wymaga IPsec VPN Gateway z NIAP-evaluated implementacją. WireGuard nie figuruje na liście PCL NIAP.

Crypto-agility: IKEv2 posiada wbudowany mechanizm negocjacji algorytmów, umożliwiający bezprzerwowe przejście na nowe algorytmy (PQC). WireGuard używa stałego zestawu algorytmów (non-negotiable).

Źródła: [CNSA-2.0], [PQC-IPSEC], [IKEv2-RFC], FIPS 140-3 CMVP database, NIAP PCL.

Warunki rewizji: Decyzja powinna być zrewidowana, jeśli: (a) WireGuard uzyska FIPS 140-3 validated module, (b) powstanie standaryzowany mechanizm PQC dla WireGuard, (c) zmieni się harmonogram CNSA 2.0.

DEC-002: Wybór Matrix jako rdzenia komunikacyjnego (zamiast Signal)

Data decyzji: 2025-09-20

Status: [CONFIRMED] — obowiązujący

Opis: SYLION stosuje protokół Matrix jako natywny rdzeń komunikacyjny. Signal Protocol jest wspierany wyłącznie jako compatibility workload (env-signal).

Uzasadnienie:

Suwerenność (Sovereignty) [MATRIX-SPEC]: Matrix umożliwia self-hosting — każdy operator posiada własną instancję homeservera w ramach swojego VPS Vault. Signal wymaga centralnych serwerów Signal Foundation — operator nie ma kontroli nad infrastrukturą.

Federacja [MATRIX-SPEC, §Federation]: Matrix obsługuje federację między instancjami — operatorzy SYLION mogą komunikować się między sobą (opt-in) bez centralnego pośrednika. Signal nie obsługuje federacji.

Transparentność [MATRIX-SPEC]: Protokół Matrix jest otwarty, specyfikacja publicznie dostępna, implementacje open-source (Synapse, Dendrite, Vodozemac). Signal Protocol jest open-source, ale infrastruktura serwerowa Signal jest zamknięta i scentralizowana.

Rozszerzalność: Matrix wspiera bridges, boty, integracje, custom room types — umożliwia budowę env-crm, env-office współdzielenia dokumentów i innych workloadów na wspólnym rdzeniu.

Analiza ryzyka centralizacji [AN0M], [ENCROCHAT]: historia platform komunikacyjnych pokazuje, że centralizacja infrastruktury jest krytycznym single point of failure. Model zdecentralizowany (Matrix) rozprasza ryzyko.

Źródła: [MATRIX-SPEC], [SIGNAL-SPEC], [AN0M], [ENCROCHAT], [GHOST].

Warunki rewizji: Decyzja powinna być zrewidowana, jeśli: (a) Signal wprowadzi wsparcie dla self-hosting i federacji, (b) powstanie nowy, otwarty protokół komunikacyjny z lepszymi właściwościami bezpieczeństwa i suwerenności, (c) pojawiają się krytyczne podatności w specyfikacji Matrix.

DEC-003: SEV-SNP jako warstwa defense-in-depth, nie absolutna granica bezpieczeństwa

Data decyzji: 2026-01-10

Status: [CONFIRMED] — obowiązujący

Opis: AMD SEV-SNP jest stosowane w SYLION jako warstwa Confidential Computing (in-use encryption), ale nie jest traktowane jako nieprzenikniona granica bezpieczeństwa. Architektura SYLION zakłada, że SEV-SNP może zostać skompromitowane, i wdraża dodatkowe warstwy ochrony.

Uzasadnienie:

Ataki Rowhammer [BATTERING-RAM]: badanie „Battering RAM” (KU Leuven, IEEE S&P 2025) demonstracyjnie przełamuje izolację SEV-SNP poprzez atak Rowhammer, umożliwiając ekstrakcję kluczy z pamięci sąsiedniej VM.

Side-channel attacks [COUNTERSEV]: badanie „CounterSEveillance” (RWTH Aachen, 2024) demonstruje atak side-channel na SEV-SNP z wykorzystaniem hardware performance counters.

Historia CVE: AMD SEV-SNP posiada historię CVE (CVE-2021-26311, CVE-2023-31315 i inne) dokumentujących podatności w firmware ASP. Każda nowa wersja firmware naprawia znane podatności, ale nie eliminuje klasy ataków.

Zasada defense-in-depth: architektura SYLION nigdy nie polega na pojedynczym mechanizmie bezpieczeństwa. SEV-SNP jest jedną z wielu warstw: mikrosegmentacja sieciowa + mTLS + efemeryczność + SEV-SNP + monitoring.

Mitigacje wdrożone: (a) obowiązkowa pamięć ECC na nodach SEV-SNP, (b) ograniczenie co-tenancy (tier STATE na dedykowanych nodach), (c) monitoring anomalii PMC, (d) regularna aktualizacja firmware ASP, (e) architektoniczna izolacja niezależna od SEV-SNP (mikrosegmentacja, mTLS).

Źródła: [BATTERING-RAM], [COUNTERSEV], [SEV-SNP], NVD CVE Database.

Warunki rewizji: Decyzja powinna być zrewidowana, jeśli: (a) AMD wprowadzi sprzętowe mitigacje Rowhammer w nowej generacji procesorów, (b) niezależny audyt potwierdzi eliminację klasy side-channel attacks w SEV-SNP, (c) Intel TDX okaże się istotnie bardziej odporny (przenieść obciążenie na TDX).

DEC-004: Blind Broker jako moduł eksperymentalny (nie normatywny)

Data decyzji: 2026-02-01

Status: [EXPERIMENTAL] — wymaga walidacji

Opis: Wzorzec Blind Broker (Session Broker i SFU bez dostępu do treści sesji) jest klasyfikowany jako eksperymentalny [E], nie normatywny [N].

Uzasadnienie:

Ograniczenia SFrame [SFRAME, RFC 9605 §7.2]: sekcja Security Considerations RFC 9605 identyfikuje ograniczenia: (a) SFrame nie chroni metadanych frame'ów (rozmiar, timing), co umożliwia traffic analysis, (b) w scenariuszach z wieloma uczestnikami, SFU musi wiedzieć, od którego uczestnika pochodzi frame (routing metadata leakage), (c) replay protection wymaga stanu na odbiorcy, co komplikuje skalowanie.

Brak dojrzałych implementacji: na dzień podjęcia decyzji, nie istnieje produkcyjnie dojrzała implementacja SFrame w kontekście SFU z pełną integracją E2EE.

Kompromis UX: Blind Broker eliminuje możliwość server-side recording, transkrypcji i moderacji — funkcje wymagane przez wielu operatorów enterprise.

Plan walidacji: (a) prototyp Blind Broker z SFrame do Q3 2026, (b) audyt bezpieczeństwa prototypu do Q4 2026, (c) decyzja o promowaniu do [R] lub utrzymaniu [E] na podstawie wyników.

Źródła: [SFRAME], [MATRIX-SPEC], wewnętrzna analiza Traffic Analysis Risk Assessment v1.0.

Warunki rewizji: Decyzja powinna być zrewidowana, jeśli: (a) specyfikacja SFrame zostanie zaktualizowana z mitygacjami dla zidentyfikowanych ograniczeń, (b) pojawi się dojrzała implementacja referencyjna, (c) MLS (Messaging Layer Security) zastąpi SFrame z lepszymi właściwościami.

Rozdział 7. Struktura książki i nawigacja

Status: [R] Rekomendowany Odbiorca: Wszyscy czytelnicy Księgi SYLION 3.0 Wpływ na baseline: Niski Powiązane rozdziały: 1.1, 5.1, 6.1

Niniejszy rozdział pełni rolę mapy i kompasu Księgi Systemu SYLION 3.0. Księga jest dokumentem obszernym (17 części, ponad 120 rozdziałów) i nie jest przeznaczona do lektury liniowej przez wszystkich czytelników. Rozdział 7 dostarcza narzędzi nawigacyjnych: wyjaśnia logikę układu, definiuje ścieżki lektury dla różnych ról i obszarów odpowiedzialności, wskazuje rozdziały krytyczne oraz mapuje treść na cykl życia produktu.

7.1 Logika układu części i rozdziałów

Status: [R] Rekomendowany Odbiorca: Wszyscy czytelnicy Wpływ na baseline: Niski Powiązane rozdziały: 7.2, 7.3, 7.5

Księga Systemu SYLION 3.0 składa się z 17 części uporządkowanych zgodnie z logiką „od fundamentów do operacji” (foundations-first). Układ odzwierciedla naturalną sekwencję zrozumienia: nie można zrozumieć architektury (Część III) bez znajomości modelu zagrożeń (Część II), ani procedur operacyjnych (Część XI) bez znajomości infrastruktury (Część VII).

Część I — Fundament (Rozdziały 1–10). Cel: ustanowienie wspólnego języka, kontekstu i ram pojęciowych dla całej Księgi. Część I nie zawiera decyzji architektonicznych — definiuje „czym jest SYLION”, „dla kogo”, „jakim językiem opisujemy system” i „skąd wiemy to, co wiemy”. Obejmuje: wizję i misję produktu (Rozdz. 1–2), filozofię bezpieczeństwa (Rozdz. 3), genezę i ewolucję od FORTRESS (Rozdz. 4), słownik i terminologię (Rozdz. 5), zasady cytowania i źródła (Rozdz. 6), strukturę książki (Rozdz. 7), governance i role (Rozdz. 8), model tierów (Rozdz. 9), certyfikację i zgodność (Rozdz. 10). Uzasadnienie umiejscowienia: fundament musi poprzedzać szczegóły — czytelnik, który przeskoczy Część I, ryzykuje nieporozumienia terminologiczne i kontekstowe w dalszych częściach.

Część II — Model zagrożeń i analiza ryzyka (Rozdziały 11–23). Cel: zdefiniowanie „przed czym chronimy” — adversary model, attack surface, threat scenarios, risk assessment. Umiejscowienie przed architekturą jest celowe: architektura SYLION jest odpowiedzią na zidentyfikowane zagrożenia, nie abstrakcyjnym projektem. Obejmuje: klasyfikację adversary (nation-state, insider, physical), analizę surface, modelowanie zagrożeń STRIDE/DREAD, analizę case studies (EncroChat, Sky ECC, ANOM, Ghost, MATRIX, BULUT), wymagania bezpieczeństwa wyprowadzone z modelu zagrożeń.

Część III — Architektura systemu (Rozdziały 24–31). Cel: opis „jak system jest zbudowany” w odpowiedzi na zagrożenia z Części II. Obejmuje: architekturę wysokiego poziomu, model stref (Zone 0–5), Split Gateway, mikrosegmentację, model tożsamości i dostępu, stos kryptograficzny (HSM/PKI/PQC), model Confidential Computing.

Część IV — Komponenty i moduły (Rozdziały 32–51). Cel: szczegółowy opis każdego komponentu systemu. Obejmuje: G1, G2, Session Broker, Access Broker, Policy Engine, env-matrix, env-signal, env-browser, env-office, env-crm, env-voice, CDR, Egress Proxy, media plane, monitoring/telemetry.

Część V — Implementacja i build (Rozdziały 52–68). Cel: jak system jest budowany — CI/CD, IaC, SBOM, secure coding, testing strategy. Adresowana głównie do zespołów Development i DevSecOps.

Część VI — Kryptografia i tożsamość (Rozdziały 69–78). Cel: głęboki opis stosu kryptograficznego, PKI, ceremonie zarządzania kluczami, FIDO2, PQC migration. Wydzielenie z Części III ze względu na objętość i specjalizację.

Część VII — Infrastruktura i wdrażanie (Rozdziały 79–82). Cel: model infrastruktury (bare metal, cloud, hybrid), wdrażanie, skalowanie, IaC patterns.

Część VIII — Operacje i monitoring (Rozdziały 83–86). Cel: operacje day-2 — monitoring, alerting, capacity planning, incident response readiness.

Część IX — Testowanie i walidacja (Rozdziały 87–92). Cel: strategia testowania — unit, integration, E2E, security testing (pentest, fuzzing, red team), compliance validation.

Część X — Bezpieczeństwo operacyjne (Rozdziały 93–97). Cel: SOC operations, threat hunting, vulnerability management, patch management, insider threat program.

Część XI — Reagowanie na incydenty (Rozdziały 98–102). Cel: incident response playbooks, forensics, communication, post-incident review, legal/regulatory notification.

Część XII — Ciągłość działania (Rozdziały 103–108). Cel: HA, DR, BCP, backup/restore, crisis management.

Część XIII — Lifecycle i zarządzanie zmianą (Rozdziały 109–113). Cel: onboarding/offboarding operatorów, change management, release management, deprecation, migration.

Część XIV — Zgodność i certyfikacja (Rozdziały 114–120). Cel: mapowanie kontroli na frameworki (NIST, ISO, FedRAMP, CC), proces certyfikacji, audit readiness.

Część XV — Partnerzy i ekosystem (Rozdziały 121–125). Cel: partner onboarding, API/SDK, marketplace, integracje.

Część XVI — Przyszłość i roadmapa (Rozdziały 126–130). Cel: technologie eksperymentalne, PQC migration roadmap, AI/ML w bezpieczeństwie, quantum readiness.

Część XVII — Załączniki (Rozdziały 131+). Cel: szablony, checklists, reference cards, decision logs, change history.

7.2 Jak czytać książkę sekwencyjnie

Status: [R] Rekomendowany Odbiorca: Nowi członkowie zespołu, architekci systemu, audytorzy zewnętrzni Wpływ na baseline: Niski Powiązane rozdziały: 7.1, 7.3, 7.5

Lektura sekwencyjna (od Rozdziału 1 do końca) jest rekomendowana dla ograniczonej grupy czytelników, którzy potrzebują holistycznego zrozumienia systemu. Dla większości czytelników lektura sekwencyjna jest nieefektywna — zalecane jest skorzystanie ze ścieżek rolowych (§7.3) lub obszarowych (§7.4).

Komu zalecana jest lektura sekwencyjna: 1. Główny Architekt Systemu (Chief Architect) — jedyna rola wymagająca pełnego zrozumienia wszystkich aspektów systemu. 2. Nowy członek Architecture Board — w ciągu pierwszych 90 dni od dołączenia. 3. Lead Auditor w procesie certyfikacji CC/FedRAMP — do budowy kontekstu przed audytem. 4. CISO operatora tieru STATE/SOVEREIGN — jeśli operator wymaga pełnej przejrzystości architektury.

Strategia lektury sekwencyjnej. Lektura sekwencyjna powinna przebiegać w trzech przebiegach o rosnącej głębokości, a nie jako jednorazowa lektura od deski do deski:

Przebieg 1 — Orientacja (szacowany czas: 4–6 godzin). Czytanie nagłówków rozdziałów i podrozdziałów, metadanych (status, odbiorca, wpływ na baseline), oraz pierwszych akapitów każdego podrozdziału. Cel: zbudowanie mapy mentalnej struktury Księgi, identyfikacja rozdziałów kluczowych dla własnej roli, zrozumienie zależności między częściami.

Przebieg 2 — Fundamenty (szacowany czas: 16–24 godziny). Pełna lektura Części I (Fundament), Części II (Model zagrożeń — rozdziały kluczowe), Części III (Architektura — rozdziały kluczowe). Po Przebiegu 2 czytelnik powinien umieć: wyjaśnić model zagrożeń SYLION, narysować architekturę wysokiego poziomu, zdefiniować granice stref bezpieczeństwa, opisać model tierów.

Przebieg 3 — Głębia (szacowany czas: 40–80 godzin, zależnie od roli). Pełna lektura wybranych części zgodnie z profilem roli. Przebieg 3 nie musi być sekwencyjny — po zbudowaniu fundamentu (Przebieg 2), czytelnik może przechodzić między częściami według potrzeb.

Tempo i retencja. Zalecane tempo: nie więcej niż 2–3 podrozdziały dziennie w Przebiegu 2. Każdy podrozdział zawiera 200–400 słów skondensowanej treści technicznej — próba przyspieszenia skutkuje utratą retencji. Zalecane: po każdym podrozdziale zapisać jednozdaniowe podsumowanie własnymi słowami (active recall).

Checkpointy weryfikacyjne. Po zakończeniu każdej Części, czytelnik powinien być w stanie odpowiedzieć na pytania kontrolne (zamieszczone na końcu każdej Części w Załącznikach). Niezdolność odpowiedzi na pytanie kontrolne wskazuje na konieczność ponownej lektury odpowiedniego rozdziału.

7.3 Jak czytać książkę według roli

Status: [R] Rekomendowany Odbiorca: Wszyscy czytelnicy Wpływ na baseline: Niski Powiązane rozdziały: 7.1, 7.2, 7.4, 7.5

Większość czytelników Księgi pełni konkretną rolę i potrzebuje podzbioru wiedzy dopasowanego do zakresu odpowiedzialności. Poniższe ścieżki rolowe definiują minimalny zestaw rozdziałów do przeczytania (mandatory) oraz rozdziały rekomendowane (recommended) dla pięciu kluczowych profili czytelnika.

Ścieżka Executive (CEO, CTO, CISO, VP Engineering, Product Director). Cel: zrozumienie wartości biznesowej, pozycji rynkowej, modelu zagrożeń na poziomie strategicznym, decyzji architektonicznych z ich uzasadnieniem, modelu zgodności. Mandatory: Część I w całości (Rozdz. 1–10), Rozdz. 11–13 (model zagrożeń — summary), Rozdz. 24–25 (architektura — high level), Rozdz. 109–110 (lifecycle — onboarding/offboarding), Rozdz. 114–116 (zgodność — overview). Recommended: Rozdz. 30 (stos kryptograficzny — overview), Rozdz. 103–105 (BCP/DR — governance), Rozdz. 126–128 (roadmapa — strategia). Szacowany czas: 12–16 godzin. Format: ścieżka Executive może być uzupełniona briefingiem prezentacyjnym (Executive Summary Deck) przygotowywanym przez Architecture Board.

Ścieżka Architect (System Architect, Security Architect, Cloud Architect, Network Architect). Cel: pełne zrozumienie architektury, decyzji projektowych, modelu zagrożeń, stosu technologicznego, wzorców integracji. Mandatory: Część I (Rozdz. 1–10), Część II w całości (Rozdz. 11–23), Część III w całości (Rozdz. 24–31), Część VI (Rozdz. 69–78 — kryptografia i tożsamość), Rozdz. 87–89 (testowanie bezpieczeństwa), Rozdz. 114–116 (zgodność — mapowanie kontroli). Recommended: Część IV (Rozdz. 32–51 — komponenty szczegółowe), Część V (Rozdz. 52–68 — implementacja), Część VII (Rozdz. 79–82 — infrastruktura), Część XII (Rozdz. 103–108 — ciągłość działania). Szacowany czas: 60–80 godzin (lektura rozłożona na 4–6 tygodni).

Ścieżka SOC (SOC Analyst, Threat Hunter, Incident Responder, Forensic Analyst). Cel: zrozumienie architektury bezpieczeństwa, modelu zagrożeń, mechanizmów detekcji, procedur reagowania, źródeł logów. Mandatory: Część I — Rozdz. 3 (filozofia bezpieczeństwa), Rozdz. 5 (słownik), Rozdz. 9 (tier), Część II (Rozdz. 11–23 — model zagrożeń), Rozdz. 24–27 (architektura — strefy, gateway, mikrosegmentacja), Część X w całości (Rozdz. 93–97 — bezpieczeństwo operacyjne), Część XI w

całości (Rozdz. 98–102 — reagowanie na incydenty). Recommended: Rozdz. 32–40 (komponenty G1, G2, brokery — szczegóły), Część VIII (Rozdz. 83–86 — monitoring), Rozdz. 69–72 (kryptografia — aby zrozumieć kontekst alertów kryptograficznych). Szacowany czas: 40–50 godzin.

Ścieżka Developer (Software Engineer, DevSecOps Engineer, SRE, QA Engineer). Cel: zrozumienie architektury implementacyjnej, wzorców kodowania, pipeline CI/CD, strategii testowania, wymagań bezpieczeństwa kodu. Mandatory: Część I — Rozdz. 3 (filozofia bezpieczeństwa), Rozdz. 5 (słownik), Część III — Rozdz. 24–25 (architektura — overview), Część IV (Rozdz. 32–51 — komponenty, które developer implementuje), Część V w całości (Rozdz. 52–68 — implementacja i build), Część IX w całości (Rozdz. 87–92 — testowanie). Recommended: Część VI (Rozdz. 69–78 — kryptografia, dla deweloperów komponentów crypto), Część VII (Rozdz. 79–82 — infrastruktura, dla SRE), Część VIII (Rozdz. 83–86 — monitoring, dla SRE). Szacowany czas: 50–60 godzin.

Ścieżka Partner (Partner Integrator, ISV, VAR, MSSP). Cel: zrozumienie modelu integracji, API/SDK, wymagań bezpieczeństwa dla partnerów, procesu certyfikacji partnera. Mandatory: Część I — Rozdz. 1–3 (wizja, misja, filozofia), Rozdz. 5 (słownik), Rozdz. 9 (tiry), Rozdz. 24–25 (architektura — overview), Część XV w całości (Rozdz. 121–125 — partnerzy i ekosystem). Recommended: Rozdz. 32–35 (komponenty — interfejsy publiczne), Rozdz. 109–111 (lifecycle — onboarding), Rozdz. 114–116 (zgodność — wymagania dla partnerów). Szacowany czas: 16–24 godziny.

7.4 Jak czytać księgę według obszaru odpowiedzialności

Status: [R] Rekomendowany Odbiorca: Wszyscy czytelnicy Wpływ na baseline: Niski Powiązane rozdziały: 7.1, 7.3, 7.5, 7.7

Alternatywą dla ścieżek rolowych (§7.3) jest nawigacja według obszaru odpowiedzialności. Ścieżka ta jest przydatna, gdy czytelnik odpowiada za konkretny domain (np. „kryptografia”, „compliance”, „incident response”) niezależnie od formalnej roli. Poniższe mapowanie łączy obszary odpowiedzialności z rozdziałami Księgi.

Obszar: Zarządzanie tożsamością i dostępem (IAM). Rozdziały kluczowe: 5.3 (słownik bezpieczeństwa — Zero Trust, FIDO2), 25 (model tożsamości i dostępu), 28 (Policy Engine i ABAC/PBAC), 69–72 (PKI, certyfikaty, FIDO2), 93 (zarządzanie uprawnieniami operacyjnymi). Kontekst uzupełniający: 3 (filozofia bezpieczeństwa), 9 (tiry — wymagania IAM per tier).

Obszar: Kryptografia i zarządzanie kluczami. Rozdziały kluczowe: 5.3 (słownik — TEE, attestation, HSM), 5.6 (akronimy kryptograficzne), 30 (stos kryptograficzny), 69–78 (Część VI — kryptografia i tożsamość w całości), 6.8 (decyzje oparte na źródłach — DEC-001, DEC-003). Kontekst uzupełniający: 24–25 (architektura — strefy, gdzie klucze są stosowane), 126–128 (roadmapa PQC).

Obszar: Infrastruktura i platforma (Cloud, Compute, Network). Rozdziały kluczowe: 5.2 (słownik architektoniczny), 26–27 (strefy, mikrosegmentacja), 79–82 (Część VII — infrastruktura), 83–86 (Część VIII — operacje), 103–108 (Część XII — ciągłość działania). Kontekst uzupełniający: 52–61 (build — IaC, CI/CD), 24–25 (architektura ogólna).

Obszar: Zgodność i certyfikacja (Compliance, Audit, Legal). Rozdziały kluczowe: 5.5 (słownik zgodności), 5.7 (akronimy regulacyjne), 10 (certyfikacja i zgodność — overview), 87–92 (Część IX — testowanie i walidacja), 114–120 (Część XIV — zgodność i certyfikacja w całości). Kontekst uzupełniający: 6 (cytowanie i źródła — jak dokumentować zgodność), 9 (tiry — wymagania compliance per tier).

Obszar: Reagowanie na incydenty i forensics. Rozdziały kluczowe: 5.3 (słownik — kill switch, duress PIN), 5.4 (słownik operacyjny — break-glass, playbook), 98–102 (Część XI — reagowanie na incydenty w całości), 93–97 (Część X — bezpieczeństwo operacyjne). Kontekst uzupełniający: 11–23 (model zagrożeń — scenariusze ataku), 83–86 (monitoring — źródła alertów).

Obszar: Rozwój produktu i roadmapa. Rozdziały kluczowe: 1–2 (wizja, misja), 4 (geneza — ewolucja od FORTRESS), 9 (tiry i segmentacja rynku), 109–113 (Część XIII — lifecycle), 126–130 (Część XVI — przyszłość i roadmapa). Kontekst uzupełniający: 5.9 (mapowanie terminów marketingowych), 121–125 (partnerzy i ekosystem).

Obszar: Komunikacja i media (Matrix, VoIP, Encryption). Rozdziały kluczowe: 5.8 (terminologia — env-matrix, env-signal, Dark-Matrix, Blind Broker), 36–40 (komponenty — env-matrix, env-signal, media plane), 6.8 (decyzje — DEC-002, DEC-004). Kontekst uzupełniający: 69–72 (kryptografia E2EE), 24–25 (architektura — data plane, media plane).

7.5 Indeks rozdziałów krytycznych

Status: [N] Normatywny Odbiorca: Wszyscy czytelnicy, Architecture Board, audytorzy Wpływ na baseline: Wysoki Powiązane rozdziały: 7.1, 7.3, 7.6

Poniższy indeks wyodrębnia ~20 rozdziałów Księgi, które stanowią obowiązkową lekturę (mandatory reading) dla każdego członka zespołu SYLION, niezależnie od roli. Rozdziały krytyczne definiują fundament wiedzy wspólnej — niezajomość któregośkolwiek z nich stanowi ryzyko dla jakości pracy i bezpieczeństwa systemu.

Kryteria włączenia do indeksu: Rozdział jest krytyczny, jeśli spełnia co najmniej dwa z trzech warunków: (a) wpływ na baseline: Krytyczny, (b) jest zależnością dla ≥5 innych rozdziałów, (c) dotyczy decyzji architektonicznej nieodwracalnej lub bardzo kosztownej w rewizji.

#	Rozdział	Temat	Uzasadnienie krytyczności
1	3	Filozofia bezpieczeństwa	Definiuje zasady nadrzędne (Zero Trust, defense-in-depth, least privilege), z których wynikają wszystkie decyzje architektoniczne
2	5	Słownik pojęć	Wspólny język — bez niego komunikacja jest niejednoznaczna
3	9	Model tierów (STANDARD/PRO/STATE)	Definiuje segmentację produktu wpływającą na każdą decyzję implementacyjną
4	10	Certyfikacja i zgodność — overview	Definiuje ramy regulacyjne determinujące wymagania architektoniczne
5	11	Adversary model	Definiuje „przed kim chronimy” — fundament threat modelu
6	13	Scenariusze zagrożeń	Konkretne scenariusze ataku, na które architektura musi odpowiedzieć
7	24	Architektura wysokiego poziomu	„Mapa” systemu — bez niej niemożliwe umiejscowienie szczegółów
8	25	Model tożsamości i dostępu	Fundament Zero Trust — jak system weryfikuje „kto” i „co wolno”
9	26	Model stref (Zone 0–5)	Fundament izolacji — gdzie są dane, kto ma dostęp
10	27	Split Gateway (G1/G2)	Kluczowy wzorec architektoniczny — defense-in-depth na bramie
11	30	Stos kryptograficzny	HSM/PKI/PQC — fundament poufności i integralności
12	31	Confidential Computing	SEV-SNP/TDX — ochrona in-use, ograniczenia, defense-in-depth

13	69	PKI i zarządzanie certyfikatami	Infrastruktura zaufania — root CA, certificate lifecycle
14	79	Model infrastruktury	Gdzie i jak system jest wdrażany — bare metal, cloud, hybrid
15	87	Strategia testowania bezpieczeństwa	Jak system jest walidowany — pentest, fuzzing, red team
16	93	Zarządzanie podatnościami	Patch management, CVE triage — operacyjne bezpieczeństwo
17	98	Incident response — procedura główna	Jak reagujemy na incydent — playbook master
18	103	HA/DR — architektura ciągłości	Jak system przetrwa awarię — RPO, RTO, failover
19	109	Onboarding operatora	Jak nowy operator wchodzi na platformę — proces end-to-end
20	114	Mapowanie kontroli na frameworki	Jak system mapuje się na NIST/ISO/FedRAMP/CC — compliance evidence

Obowiązek lektury. Każdy nowy członek zespołu SYLION (inżynier, architekt, operator, PM, QA) musi przeczytać wszystkie 20 rozdziałów krytycznych w ciągu pierwszych 60 dni od dołączenia. Potwierdzenie lektury jest elementem procesu onboardingu pracownika.

7.6 Rozdziały normatywne vs informacyjne

Status: [N] Normatywny Odbiorca: Wszyscy autorzy i czytelnicy dokumentacji Wpływ na baseline: Wysoki Powiązane rozdziały: 6.5, 7.1, 7.5

Każdy podrozdział Księgi SYLION 3.0 posiada status zdefiniowany w metadanych nagłówka. Rozróżnienie między rozdziałami normatywnymi a informacyjnymi jest fundamentalne dla poprawnej interpretacji treści i podejmowania decyzji.

Rozdziały normatywne — status [N]. Rozdziały normatywne zawierają wymagania obowiązkowe (musi), silne rekomendacje (powinien) i warunki (może). Treść rozdziałów normatywnych jest wiążąca — odchylenie od wymagań normatywnych wymaga formalnej procedury Deviation Request, zatwierdzenia przez Architecture Board i odnotowania w Rejestrze Odchyłeń. Rozdziały normatywne stanowią podstawę: (a) audytów wewnętrznych i zewnętrznych, (b) certyfikacji (CC, FedRAMP, SOC 2), (c) SLA z operatorami, (d) kryteriów akceptacji w procesie testowania. Język normatywny: „musi” = obowiązkowe (SHALL), „powinien” = silna rekomendacja, odchylenie wymaga uzasadnienia i zatwierdzenia (SHOULD), „może” = opcjonalne, do decyzji implementatora/operatora (MAY). Konwencja ta jest zgodna z RFC 2119 / BCP 14.

Przykładowe rozdziały normatywne: 3 (filozofia bezpieczeństwa), 5 (słownik), 9 (model tierów — baseline requirements), 24–31 (architektura), 69–78 (kryptografia), 87–92 (testowanie — minimalne wymagania), 93–97 (bezpieczeństwo operacyjne — obligatoryjne kontrole), 98–102 (incident response — procedury obowiązkowe).

Rozdziały rekomendowane — status [R]. Rozdziały rekomendowane zawierają best practices, wzorce referencyjne i wytyczne, które stanowią silną rekomendację, ale dopuszczają alternatywne podejścia, pod warunkiem że alternatywa spełnia ten sam cel bezpieczeństwa/jakości. Odchylenie od rekomendacji [R] wymaga udokumentowania uzasadnienia, ale nie wymaga formalnego Deviation Request. Rozdziały rekomendowane stanowią podstawę: (a) review architektonicznych, (b) szkoleń, (c) planowania roadmapy. Przykładowe rozdziały rekomendowane: 7 (struktura książki), 52–61 (implementacja — patterns), 83–86 (monitoring — rekomendowane tooling).

Rozdziały opcjonalne — status [O]. Rozdziały opcjonalne opisują funkcjonalności lub konfiguracje dostępne, ale niezobowiązujące. Stosowanie treści [O] zależy od decyzji operatora, tieru, jurysdykcji lub konkretnego deployment. Przykłady: konfiguracja Dark-Matrix, integracje z systemami zewnętrznymi specyficznymi dla branży, rozszerzenia API.

Rozdziały eksperymentalne — status [E]. Rozdziały eksperymentalne opisują technologie, wzorce lub funkcjonalności w fazie badawczej, które nie są jeszcze rekomendowane do wdrożenia produkcyjnego. Treść [E] musi być traktowana jako hipotetyczna — nie może stanowić podstawy decyzji architektonicznych ani zobowiązań wobec operatorów. Każdy rozdział [E] posiada plan walidacji z harmonogramem. Przykłady: Blind Broker (\$5.8), Dark-Matrix (\$5.8), SFrame media encryption.

Rozdziały autonomiczne — status [A]. Rozdziały autonomiczne opisują moduły systemu funkcjonujące poza certifiable core. Treść [A] podlega standardowym procesom jakości, ale nie formalnej certyfikacji. Moduły [A] mogą być aktualizowane niezależnie od rdzenia. Przykłady: env-browser, env-office, env-crm, dashboardsy administracyjne.

Matryca statusów i konsekwencji:

Status	Zmiana wymaga	Audyt obejmuje	Certyfikacja obejmuje	Język normatywny
[N]	Deviation Request + Architecture Board	Tak	Tak (certifiable core)	musi/powinien/może
[R]	Udokumentowane uzasadnienie	Tak (advisory)	Nie bezpośrednio	powinien/może
[O]	Decyzja operatora/tieru	Na żądanie	Nie	może
[E]	Plan walidacji	Nie (dopóki nie promowane)	Nie	wymaga walidacji
[A]	Standard CI/CD	Tak (standard)	Nie (poza certifiable core)	powinien/może

7.7 Mapowanie rozdziałów do SDLC i lifecycle produktu

Status: [R] Rekomendowany Odbiorca: Product Management, Engineering Leadership, DevSecOps, QA Wpływ na baseline: Średni Powiązane rozdziały: 7.1, 7.4, 7.5

Mapowanie rozdziałów Księgi na fazy SDLC (Software Development Lifecycle) i lifecycle produktu umożliwia zespołom szybkie znalezienie treści relewantnej dla aktualnej fazy pracy. Mapowanie jest szczególnie przydatne dla: planowania sprintów (jakie rozdziały są źródłem wymagań), review architektonicznych (jakie rozdziały definiują kryteria), gate’ów jakościowych (jakie rozdziały definiują kryteria przejścia).

Faza: Design (Projektowanie) → Rozdziały 24–31. Obejmuje: definiowanie architektury, wymagań bezpieczeństwa, decyzji technologicznych. Rozdziały kluczowe: 24 (architektura wysokiego poziomu), 25 (model tożsamości), 26 (model stref), 27 (Split Gateway), 28 (Policy Engine), 29 (mikrosegmentacja — szczegóły), 30 (stos kryptograficzny), 31 (Confidential Computing). Sposób użycia: rozdziały 24–31 stanowią „specyfikację architektoniczną” — każda decyzja implementacyjna musi być traceable do wymagania z tych rozdziałów. Architecture Review Board weryfikuje zgodność designu z Częścią III przed przejściem do fazy Build.

Faza: Build (Implementacja) → Rozdziały 52–61, 69, 80. Obejmuje: kodowanie, konfiguracja, budowanie artefaktów, CI/CD pipeline. Rozdziały kluczowe: 52 (secure coding guidelines), 53 (CI/CD pipeline — wymagania bezpieczeństwa), 54 (SBOM — generowanie i walidacja), 55 (dependency management — SCA), 56 (IaC patterns), 57 (container/microVM image building), 58 (secret management w pipeline), 59 (code review — wymagania), 60 (static analysis — SAST), 61 (dynamic analysis — DAST), 69 (PKI — emisja certyfikatów w build), 80 (provisioning — IaC deployment). Sposób użycia: rozdziały 52–61 definiują „jak budować bezpiecznie” — kryteria merge request review, quality gates w CI/CD, wymagania dla artefaktów (podpis cyfrowy, SBOM, scan results).

Faza: Test (Testowanie i walidacja) → Rozdziały 87–92. Obejmuje: testowanie bezpieczeństwa, testy funkcjonalne, testy wydajnościowe, walidacja zgodności. Rozdziały kluczowe: 87 (strategia testowania bezpieczeństwa — pentest, fuzzing, red team), 88 (testy compliance — SCAP, STIG validation), 89 (testy E2E — scenariusze end-to-end), 90 (testy wydajnościowe — load, stress, chaos engineering), 91 (testy kryptograficzne — walidacja algorytmów, key management), 92 (testy regresji bezpieczeństwa — po każdej zmianie w certifiable core). Sposób użycia: rozdziały 87–92 definiują „co musi przejść” przed wdrożeniem — test exit criteria, minimum test coverage, obligatory test types per tier.

Faza: Deploy (Wdrożenie) → Rozdziały 79, 109–113. Obejmuje: wdrażanie na środowiska (staging, production), onboarding operatorów, release management. Rozdziały kluczowe: 79 (model infrastruktury — target environments), 109 (onboarding operatora — proces wdrożenia), 110 (offboarding operatora — proces zakończenia), 111 (change management — release process), 112 (rollback procedures), 113 (deprecation i migration — EOL management). Sposób użycia: rozdziały 79 i 109–113 definiują „jak wdrażać” i „jak zarządzać zmianą” — deployment checklists, rollback criteria, operator acceptance testing.

Faza: Operate (Operacje) → Rozdziały 83–86, 93–97. Obejmuje: monitoring, alerting, vulnerability management, patch management, day-2 operations. Rozdziały kluczowe: 83 (monitoring i observability — stack, metryki), 84 (alerting — reguły, eskalacja, runbooks), 85 (capacity planning — skalowanie, limity), 86 (maintenance — windows, upgrades, rotation), 93 (vulnerability management — CVE triage, patching), 94 (threat hunting — proactive detection), 95 (insider threat program), 96 (access review — periodic recertification), 97 (security posture assessment — continuous compliance). Sposób użycia: rozdziały 83–86 i 93–97 stanowią „instrukcję obsługi” platformy w stanie operacyjnym — SLI/SLO definitions, alert triage playbooks, patch windows, compliance dashboards.

Faza: Respond (Reagowanie na incydenty) → Rozdziały 98–102. Obejmuje: incident detection, triage, containment, eradication, recovery, post-incident review, legal/regulatory notification. Rozdziały kluczowe: 98 (incident response — master playbook, severity classification, RACI), 99 (containment i eradication — procedury per severity), 100 (forensics — evidence collection, chain of custody, Zone 4 analysis), 101 (communication — internal, operator, regulatory, media), 102 (post-incident review — RCA, lessons learned, improvement actions). Sposób użycia: rozdziały 98–102 są „planem awaryjnym” — nie czytaj ich po raz pierwszy w trakcie incydentu. Każdy członek zespołu z rolą incident response musi zapoznać się z nimi proaktywnie i uczestniczyć w ćwiczeniach (tabletop exercises minimum raz na kwartał).

Macierz podsumowująca:

Faza SDLC	Rozdziały główne	Artefakt wyjściowy fazy	Gate przejścia
Design	24–31	Architecture Decision Records, Threat Model, Security Architecture Document	Architecture Review Board approval
Build	52–61, 69, 80	Signed artifacts, SBOM, SAST/SCA reports, Code review approvals	CI/CD quality gates pass
Test	87–92	Pentest report, Compliance scan, E2E test results, Performance benchmarks	Test exit criteria met
Deploy	79, 109–113	Deployment checklist, Operator acceptance, Rollback plan	Change Advisory Board approval
Operate	83–86, 93–97	Monitoring dashboards, SLO reports, Vulnerability status, Access review	Continuous compliance checks
Respond	98–102	Incident report, RCA, Improvement actions, Regulatory notification (if applicable)	Post-incident review completion

11.8 Koniec Rozdziałów 5–7 Części I Księgi Systemu SYLION 3.0.

title: “KSIĘGA SYLION 3.0 — CZĘŚĆ II” subtitle: “Wizja produktu, strategia i model biznesowy” version: “3.0.1” date: “Kwiecień 2026” classification: “POUFNE / CONFIDENTIAL” status: “Dokument Normatywny — Wersja Robocza” — partnerów Właściciel dokumentu: Architekt Główny SYLION

CZĘŚĆ II — WIZJA PRODUKTU, STRATEGIA I MODEL BIZNESOWY

Rozdział 8. Wizja produktu i misja SYLION 3.0

8.1 Wizja SYLION 3.0

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Dev | Infra | SOC | Compliance | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.2, 8.3, 8.5, 9.1, 10.1

„Kompromitacja urządzenia końcowego nie może oznaczać kompromitacji danych, komunikacji ani tożsamości operatora.”

Wizja SYLION 3.0 wyrasta z jednego fundamentalnego przekonania: era zaufania do endpointów dobiegła końca. Przez dwie dekady branża cyberbezpieczeństwa inwestowała miliardy w ochronę urządzeń końcowych — antywirusy, EDR, MDM, szyfrowanie dysków, bezpieczne kontenery — zakładając, że odpowiednio zahartowane urządzenie stanowi wiarygodną granicę bezpieczeństwa. Historia platform kryptokomunikacyjnych (EncroChat, Sky ECC, ANOM, Ghost, MATRIX) oraz zaawansowanych ataków na endpointy (Pegasus, Predator, Hermit) jednoznacznie wykazała, że założenie to jest architektonicznie błędne.

SYLION 3.0 przenosi granicę zaufania z urządzenia końcowego do kontrolowanego środowiska chmurowego. Terminal — telefon z GrapheneOS (Google Pixel najnowszej dostępnej generacji) lub zarządzany laptop — pełni rolę zero-knowledge pixel renderera: wyświetla wyłącznie piksele i odtwarza audio, nie przechowuje żadnych danych, kluczy, historii komunikacji ani sesji. Wszystkie aplikacje, dane, kanały komunikacyjne i tożsamości kryptograficzne rezydują w izolowanym środowisku VPS w chmurze, odseparowanym per-operator za pomocą mikrosegmentacji, mikroVM Firecracker oraz architektury Split Gateway G1/G2.

Wizja ta nie jest abstrakcyjnym ideałem — jest architektonicznie egzekwowalnym wymaganiem, które musi przenikać każdą decyzję projektową, implementacyjną i operacyjną w ekosystemie SYLION. Każdy komponent, który narusza tę wizję — przechowując dane na terminalu, eksponując klucze w pamięci endpointu lub umożliwiając ekstrakcję sesji z urządzenia — stanowi defekt architektoniczny i musi zostać wyeliminowany przed dopuszczeniem do baseline produkcyjnego.

Wizja implikuje trzy nienaruszalne właściwości systemu: (1) zero danych w spoczynku na terminalu — żadne dane biznesowe, kryptograficzne ani komunikacyjne nie mogą być trwale zapisane na urządzeniu końcowym; (2) zero kluczy na terminalu — materiał kryptograficzny rezyduje w HSM/VPS, terminal nie posiada zdolności deszyfrowania danych; (3) zero sesji przetrwałych — utrata, konfiskata lub infekcja terminala kończy sesję pikselową bez kompromitacji jakichkolwiek danych.

8.2 Misja produktu

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.1, 8.3, 9.1, 10.1, 10.2

Misja SYLION 3.0 brzmi: dostarczyć certyfikowalną, zdolną do suwerennego wdrożenia platformę bezpiecznej pracy i komunikacji, którą każda organizacja może wdrożyć niezależnie od tego, czy ufa swoim urządzeniom, sieciom, a nawet dostawcom chmurowym.

Misja ta zawiera cztery celowe kwalifikatory, z których każdy determinuje istotne decyzje architektoniczne i biznesowe:

Certyfikowalność oznacza, że architektura SYLION musi być od pierwszego dnia projektowana z myślą o procesach certyfikacyjnych — FIPS 140-3 dla modułów kryptograficznych, Common Criteria dla rdzenia systemu, FedRAMP dla wdrożeń federalnych, ISO 27001 dla zarządzania bezpieczeństwem informacji.

Certyfikowalność nie jest cechą dodawaną post factum; wymaga separacji rdzenia certyfikowalnego od modułów autonomicznych, formalnej dokumentacji architektonicznej (niniejsza Księga) oraz ciągłego audytu zgodności. Harmonogram certyfikacyjny jest precyzyjnie zdefiniowany: ISO 27001 w Roku 1, FIPS 140-3 w Roku 2, Common Criteria EAL4+ w Roku 3.

Zdolność do suwerennego wdrożenia oznacza, że klient — w szczególności podmiot publiczny lub organizacja podlegająca restrykcjom jurysdykcyjnym — musi mieć techniczną możliwość wdrożenia i operowania platformą bez zależności od zewnętrznych dostawców chmurowych, zagranicznych jurysdykcji czy pojedynczego punktu awarii kontrolowanego przez stronę trzecią. Architektura SYLION musi wspierać wdrożenie on-premise, w chmurze prywatnej lub w konfiguracji hybrydowej z lokalnymi HSM i zarządzaniem kluczami. Struktura korporacyjna SYLION — z Aktiengesellschaft w Szwajcarii jako głównym podmiotem prawnym — celowo minimalizuje ekspozycję na jurysdykcje objęte CLOUD Act.

Bezpieczna praca i komunikacja definiuje SYLION jako platformę pełnozakresową — nie tylko bezpieczny komunikator, lecz kompletne środowisko pracy zdalnej obejmujące: komunikację (Matrix jako rdzeń, voice/video, messaging), dokumenty (środowisko biurowe), CRM, przeglądarkę internetową, analitykę i integracje.

Misja wyklucza pozycjonowanie SYLION jako niszowego narzędzia komunikacyjnego.

Koszty założenia spółki w Szwajcarii. GmbH (odpowiednik sp. z o.o.): koszt rejestracji CHF 3 000–6 000 (notariusz, Handelsregister, dokumenty), minimalny kapitał zakładowy CHF 20 000, czas rejestracji 2–4 tygodnie, pełna własność zagraniczna dozwolona. CIT w kantonie Zug od 11.85% (jeden z najniższych w Europie).

Szwajcaria nie jest członkiem UE/EOG, ale posiada decyzję adekwatności UE — dane mogą swobodnie przepływać z EU. Nie jest członkiem Five Eyes, Nine Eyes ani Fourteen Eyes. Zagraniczne żądania prawne muszą przejść test podwójnej karalności.

Niezależność od zaufania jest najambitniejszym elementem misji. SYLION musi działać poprawnie i bezpiecznie nawet gdy: (a) urządzenie końcowe jest skompromitowane; (b) sieć jest kontrolowana przez adwersarza; (c) dostawca chmurowy jest zmuszony do współpracy z organami obcej jurysdykcji. Architektura Zero Trust, Split Gateway, Confidential Computing (SEV-SNP/TDX) i suwerenne wdrożenie są realizacją tej właśnie zasady.

8.3 Problem, który system rozwiązuje

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.1, 8.4, 8.5, 12.1, 12.5

SYLION 3.0 adresuje fundamentalny defekt architektoniczny dominujący w branży cyberbezpieczeństwa od ponad dwóch dekad: traktowanie urządzenia końcowego jako ostatniej linii obrony (endpoint-as-last-line-of-defense). Model ten zakłada, że jeśli wystarczająco dobrze zabezpieczymy endpoint — zaszyfrujemy dysk, zainstalujemy EDR, wdrożymy MDM, skonfigurujemy VPN — to nawet w przypadku fizycznej utraty urządzenia lub ataku sieciowego dane pozostaną bezpieczne.

Założenie to jest architektonicznie złamane z kilku powodów. Po pierwsze, endpoint zawsze jest podatny na ataki zero-day i zero-click. Pegasus (NSO Group) demonstrował wielokrotnie zdolność do przejęcia pełnej kontroli nad urządzeniem bez jakiegokolwiek interakcji użytkownika — poprzez exploity w iMessage,

WhatsApp i innych wektorach. Żaden poziom zabezpieczeń endpointowych nie chroni przed nieznanym exploitem w jądrze systemu operacyjnego. Po drugie, fizyczna konfiskata urządzenia — na granicy, podczas kontroli, w wyniku kradzieży — ekspozuje zaszyfrowane dane na atak brute-force, cold boot lub chip-off. Czas to jedyna obrona, a czas jest po stronie adversarza. Po trzecie, malware na endpointzie widzi dane przed szyfrowaniem i po deszyfrowaniu — dokładnie ten wektor wykorzystano przy eliminacji EncroChat, gdzie francuska żandarmeria wdrożyła implanty odczytujące wiadomości z pamięci urządzenia zanim zostały zaszyfrowane. Po czwarte, ataki na warstwę sieciową (SS7 interception, IMSI catchers, rogue base stations) umożliwiają przechwytywanie komunikacji na poziomie, którego zabezpieczenia endpointowe nie adresują.

Tradycyjne rozwiązania enterprise — VDI, MDM, VPN, RBI — adresują fragmenty problemu, lecz żadne z nich nie eliminuje fundamentalnej zależności od zaufania endpointowi. VDI wciąż wymaga zaufanego systemu operacyjnego na kliencie, MDM wciąż pozostawia dane na urządzeniu, VPN zabezpiecza transport lecz nie chroni danych w spoczynku na endpointzie, a RBI izoluje jedynie przeglądarkę, nie obejmując pełnego środowiska pracy.

SYLION rozwiązuje ten problem architektonicznie: eliminuje endpoint jako granicę bezpieczeństwa. Terminal nie posiada danych, kluczy ani sesji — skompromitowany, skonfiskowany lub zainfekowany terminal równa się zerowemu wyciekowi informacji. Dla kancelarii prawnej obsługującej wrażliwą sprawę, dla dziennikarza śledczego chroniącego źródła, dla polityka opozycji narażonego na inwigilację państwową — ta architektoniczna gwarancja jest fundamentalna.

8.4 Dlaczego klasyczne podejście do endpointów zawiodło

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 8.3, 8.5, 12.1, 12.5, 12.6

Analiza ośmiu eliminacji platform kryptokomunikacyjnych w latach 2018–2025 ujawnia powtarzające się wzorce awarii, z których każdy potwierdza fundamentalną słabość modelu endpoint-centric:

EncroChat (2020): Francuska żandarmeria (C3N) we współpracy z holenderską policją wdrożyła implanty na serwerze aktualizacji EncroChat, które zostały wypchane do urządzeń końcowych jako aktualizacja oprogramowania. Implanty odczytywały wiadomości z pamięci urządzenia przed szyfrowaniem — klucze szyfrujące, mimo poprawnej implementacji, stały się bezużyteczne, ponieważ malware operował na tym samym endpoint co aplikacja. Eliminacja objęła ponad 60 000 urządzeń. Wzorzec awarii: zaufanie do endpointu + scentralizowany serwer aktualizacji = single point of compromise.

Sky ECC (2021): Belgijska policja federalna przejęła komunikację poprzez mechanizm silent push messages, który ekstrahował klucze kryptograficzne bezpośrednio z telefonów. Ponad 170 000 urządzeń zostało skompromitowanych. Wzorzec awarii: materiał kryptograficzny na endpointzie + niewidoczny kanał ekstrakcji.

ANOM / ANOM (2021): FBI stworzyło platformę komunikacyjną od podstaw, wbudowując backdoor umożliwiający kopiowanie każdej wiadomości do serwera FBI. Ponad 12 000 urządzeń w 100 krajach. Wzorzec awarii: scentralizowana kontrola infrastruktury + ślepe zaufanie użytkowników do dostawcy.

Ghost (2024): Australijska policja federalna (AFP) we współpracy z francuskimi specjalistami kryptograficznymi przejęła serwery administracyjne i wypchnęła zainfekowane aktualizacje do urządzeń końcowych. Wzorzec awarii: identyczny z EncroChat — scentralizowane aktualizacje + endpoint trust.

MATRIX (Operacja Passionflower, 2024): Europol, w kooperacji z holenderską i francuską policją, przejął serwery platformy MATRIX, umożliwiając dekryptację komunikacji w czasie rzeczywistym. Wzorzec awarii: scentralizowana infrastruktura + brak mikrosegmentacji.

Exclu (2023): Holenderska policja przeniknęła infrastrukturę, uzyskując dostęp do wiadomości. Wzorzec awarii: współdzielona infrastruktura bez izolacji per-operator.

Operacja BULUT (2025): Koordynowana przez Europol operacja wykorzystała dane odszyfrowane z platform Sky ECC i ANOM, prowadząc do 232 aresztowań i zajęcia aktywów wartości ponad 300 milionów euro w sześciu krajach. Wzorzec awarii: dane kryptokomunikacyjne zachowane na serwerach = trwałe ryzyko nawet lata po eliminacji platformy.

Wspólne tryby awarii: (1) scentralizowana infrastruktura jako SPOF; (2) zaufanie do endpointu; (3) współdzielone klucze lub brak izolacji kryptograficznej per-operator; (4) ekspozycja metadanych; (5) słabość jurysdykcyjna — serwery w jurysdykcjach współpracujących z organami ścigania.

SYLION 3.0 adresuje każdy z tych trybów awarii architektonicznie: brak danych na endpointzie eliminuje (1) i (2), mikrosegmentacja per-operator eliminuje (3), minimalizacja metadanych i kontrola egress adresuje (4), a zdolność do suwerennego wdrożenia — ze strukturą korporacyjną opartą na szwajcarskiej Aktiengesellschaft wolnej od ekspozycji CLOUD Act — adresuje (5).

8.5 Thin client jako założenie strategiczne

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Dev | Infra | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.1, 8.3, 8.4, 8.6, 12.7

Wybór modelu Thin Client nie jest kompromisem inżynierskim ani ograniczeniem budżetowym — jest fundamentalnym założeniem strategicznym, na którym opiera się cała architektura SYLION 3.0. Terminal pełni rolę ślepego renderera pikseli i audio: odbiera zaszyfrowany strumień pikselowy z chmurowego VPS operatora, dekoduje go lokalnie i wyświetla na ekranie. Ruch wejściowy (dotyk, klawiatura, ruchy kursora) jest przesyłany z powrotem do VPS. Na terminalu nie rezydują żadne dane biznesowe, klucze kryptograficzne, historia komunikacji, tokeny sesji ani pliki.

Ta architektura oznacza, że skradziony terminal = zero danych. Adversarz pozyskujący urządzenie fizycznie — przez kradzież, konfiskatę na granicy, przeszukanie czy atak fizyczny — uzyskuje wyłącznie sprzęt z systemem operacyjnym GrapheneOS (lub zarządzanym Linux). Nie ma na nim żadnych danych do odzyskania, żadnych kluczy do wyekstrahowania, żadnej historii komunikacji do odczytania. Nawet analiza forensyczna najwyższej klasy (chip-off, JTAG, cold boot) nie ujawni danych biznesowych, ponieważ dane te nigdy nie zostały zapisane na urządzeniu.

Zainfekowany terminal = strumień pikseli. Nawet jeśli adversarz wdroży na terminalu zaawansowany implant (Pegasus-class), jedyne co może przechwycić to: strumień pikselowy wyświetlany na ekranie (który traci wartość po zakończeniu sesji), dane wejściowe użytkownika (dotyk/klawiatura) oraz ewentualnie audio z mikrofonu/głośnika. Implant nie ma dostępu do danych w spoczynku (nie ma ich), kluczy kryptograficznych (rezydują w HSM/VPS) ani pełnej historii komunikacji (nie istnieje lokalnie).

Porównanie z alternatywami architektonicznymi: VDI (Citrix, VMware Horizon) działa na podobnej zasadzie zdalnego pulpitu, lecz wymaga zaufanego systemu operacyjnego na kliencie, nie zapewnia izolacji per-użytkownik (współdzielona farma serwerów) i nie integruje Zero Trust ani CDR. MDM (Intune, Jamf, SOTI) zabezpiecza urządzenie, lecz dane wciąż na nim rezydują — szyfrowanie dysku jest jedyną obroną przed fizycznym dostępem. VPN (IPsec, SSL) zabezpiecza transport, lecz nie adresuje danych w spoczynku na endpointzie. RBI (Remote Browser Isolation) izoluje wyłącznie przeglądarkę — nie obejmując komunikacji, dokumentów, CRM ani innych środowisk pracy.

Model Thin Client SYLION łączy zalety VDI (zdalne wykonanie) z Zero Trust (brak domniemanego zaufania), mikrosegmentacją per-operator (izolacja na poziomie workloadu) i CDR (bezpieczny transfer plików). Żadna z alternatyw nie łączy tych czterech elementów w jedną architekturę. Pakiet hardware'owy SYLION — obejmujący Google Pixel najnowszej generacji, router podrzędny GL-iNet Beryl AX (MT-3000) z obsługą OpenWrt + IPsec IKEv2 oraz biometryczny klucz FIDO2 (YubiKey Bio) — stanowi kompletny, gotowy do pracy zestaw terminalowy o wartości 1 250 € per operator (jednorazowo), zapewniający natychmiastową operacyjność.

8.6 Pozycja SYLION jako platformy komunikacji i pracy zdalnej

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 8.1, 8.2, 8.5, 10.1, 10.2, 12.5, 12.6, 13.1

SYLION 3.0 nie jest bezpiecznym komunikatorem — jest platformą bezpiecznej pracy zdalnej (Secure Remote Work Platform). Rozróżnienie to jest fundamentalne dla pozycjonowania produktu, strategii sprzedaży i architektury systemu.

Pozycja „bezpieczny komunikator” implikuje wąski zakres funkcjonalny: szyfrowane wiadomości, połączenia głosowe i wideo. Rynek bezpiecznych komunikatorów jest zatłoczony (Signal, Threema, Wickr, Element) i zdominowany przez rozwiązania open-source lub darmowe, co ogranicza potencjał monetizacyjny i utrudnia uzasadnienie cen enterprise/government. Ponadto „bezpieczny komunikator” nie adresuje pełnego spektrum zagrożeń — chroni jedynie jeden kanał, pozostawiając dokumenty, CRM, przeglądanie internetu i inne czynności pracy poza ochroną.

SYLION pozycjonuje się jako bezpieczny zdalny system operacyjny (Secure Remote OS), który w jednym izolowanym środowisku chmurowym udostępnia operatorowi komplet narzędzi pracy:

Komunikacja: Matrix jako rdzeń (messaging, voice, video, rooms, federacja kontrolowana), z Signal jako degradowanym workloadem kompatybilnościowym dla komunikacji z kontaktami zewnętrznymi używającymi Signal.

Dokumenty i produktywność: Środowisko biurowe (env-office) z pakietem kompatybilnym z formatami Microsoft Office, edycja dokumentów, arkusze kalkulacyjnych i prezentacji w izolowanym środowisku.

CRM i analityka: Środowisko CRM (env-crm) z kontrolowanym dostępem API do systemów zewnętrznych, analityka operacyjna.

Przeglądarka internetowa: Środowisko przeglądarkowe (env-browser) z routingiem przez egress proxy, kontrolą ruchu wychodzącego i izolacją od środowisk komunikacyjnych.

Voice/Video konferencje: Natywne konferencje w ramach tenant Matrix, z opcjonalnym Blind Broker dla dodatkowej prywatności audio/video (SFrame — status [R] dla audio/video, [E] dla kanału remote desktop).

Integracje: API bridge dla integracji z systemami zewnętrznymi (SIEM, ticketing, ERP), z kontrolą przepływu danych przez CDR staging.

Ta pozycja umożliwia SYLION adresowanie budżetów bezpieczeństwa IT (nie tylko budżetów komunikacyjnych), konkurowanie z rozwiązaniami VDI/ZTNA (nie tylko z komunikatorami) oraz uzasadnienie cen per-operator na poziomie 400–2 500+ € miesięcznie — adekwatnych dla platform enterprise, nie dla aplikacji komunikacyjnej. Pozycja „Secure Remote OS” jest unikalna na rynku — Hypori (najbliższy konkurent) pozycjonuje się jako „secure BYOD”, koncentrując się głównie na bezpiecznym przesyłaniu wiadomości mobilnych, a nie jako pełna platforma pracy obejmująca Matrix + Office + CRM + Browser + Analytics + Voice.

8.7 Zakładana ewolucja produktu w czasie

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Dev | Partner Wpływ na baseline: Średni Powiązane rozdziały: 8.8, 9.1, 9.5, 16.1

Ewolucja produktu SYLION 3.0 jest planowana w czterech horyzontach, z których każdy wprowadza nowe zdolności i adresuje nowe segmenty rynku. Horyzonty nie są sztywnymi fazami waterfall — stanowią orientacyjne ramy planistyczne podlegające adaptacji w odpowiedzi na sygnały rynkowe, postęp certyfikacyjny i feedback klientów.

Horyzont 1 — 2026: Rdzeń platformy i Faza 1 GTM. Celem jest dostarczenie produkcyjnie gotowego rdzenia platformy obejmującego tier STANDARD (400 €/operator/miesiąc) i PRO (1 500 €/operator/miesiąc), z pełnym stosem komunikacyjnym Matrix, środowiskami pracy zdalnej (office, CRM, browser), architekturą Split Gateway G1/G2, mikrosegmentacją per-operator, infrastrukturą immutable na Firecracker microVM oraz IPsec IKEv2 jako transportem. Rdzeń certyfikowalny musi być formalnie oddzielony od modułów autonomicznych. Uruchomienie procesu certyfikacji ISO 27001. Pierwsze wdrożenia u klientów europejskich: kancelarie prawne, dziennikarze śledczy, politycy opozycji, organizacje praw człowieka. Cel ARR Roku 1: ~2 mln €.

Horyzont 2 — 2027: Tier suwerenny i certyfikacje. Wdrożenie tieru STATE/SOVEREIGN (od 2 500 €/operator/miesiąc, minimum 50 operatorów = minimum 125 000 €/miesiąc per klient = 1,5 mln €/rok per klient) z pełnym wsparciem on-premise, lokalnymi HSM, izolacją jurysdykcyjną i kontrolą nad materiałem kryptograficznym. Certyfikacja ISO 27001 zakończona. Inicjacja ścieżki FIPS 140-3. Rozszerzenie ekosystemu partnerów integracyjnych. Wejście do segmentu defence-adjacent: kontrahenci wojskowi, konsultanci obronni, biura bezpieczeństwa parlamentarnego. Cel ARR Roku 3: ~10 mln €.

Horyzont 3 — 2028: PQC, Confidential Computing i rynek US. Pełne wdrożenie kryptografii post-quantum (PQC) w protokołach transportowych i w warstwie danych w spoczynku. Confidential Computing (AMD SEV-SNP / Intel TDX) jako baseline dla tieru STATE — z transparentnym opisem ograniczeń. Certyfikacja Common Criteria EAL4+ dla rdzenia. Wejście na rynek północnoamerykański przez istniejące europejskie referencje klientów: kancelarie prawne US, dziennikarze US (kultura ochrony Pierwszej Poprawki). Inicjacja procesu FedRAMP. Partnerstwo z US-based MSSP dla dystrybucji.

Horyzont 4 — 2029+: Wdrożenie sfederowane i tryb air-gap. Wdrożenie sfederowane umożliwiające dystrybucję infrastruktury SYLION między wiele jurysdykcji z zachowaniem spójnego zarządzania. Tryb air-gap dla wdrożeń całkowicie odizolowanych od internetu (intelligence, military-adjacent). Post-quantum PKI jako domyślny stos. Autoryzacja FedRAMP High jako cel (2–3 lata po wejściu europejskim). Cel: SYLION jako standardowa infrastruktura suwerennych organizacji globalnie.

8.8 Docelowy obraz produktu za 3, 5 i 10 lat

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Niski Powiązane rozdziały: 8.7, 9.1, 9.7, 16.1, 16.10

Perspektywa 3-letnia (2029): SYLION jest wiodącą platformą bezpiecznej komunikacji i pracy zdalnej na europejskim rynku regulowanym. ARR przekracza 10 mln €. Platforma obsługuje ~850 operatorów w trzech tierach: 500 STANDARD (200 000 €/miesiąc), 200 PRO (300 000 €/miesiąc), 150 STATE w 3 kontraktach (375 000

€/miesiąc). Rdeń certyfikowalny przeszedł certyfikację Common Criteria EAL4+ i FIPS 140-3 Level 2+. Ekosystem obejmuje minimum 5 certyfikowanych partnerów integracyjnych. Moduł PQC jest dostępny jako opcja produkcyjna ([R] dla tieru STATE). Struktura korporacyjna obejmuje Swiss AG, US LLC/Corp i polską Sp. z o.o. operacyjną.

Perspektywa 5-letnia (2031): SYLION posiada autoryzację FedRAMP High, umożliwiając wdrożenia w agencjach federalnych USA i u kontrahentów DoD. Wdrożenia NATO-adjacent aktywne. Ekosystem obejmuje ponad 10 certyfikowanych integratorów w Europie i Ameryce Północnej. Confidential Computing jest baseline dla tieru STATE. Model federacji umożliwia kontrolowane połączenia między suwerennymi instancjami SYLION w różnych jurysdykcjach. Segmenty journalism/NGO/diplomacy obsługiwane z dedykowanym tierem. Łączna liczba operatorów przekracza 25 000 globalnie.

Perspektywa 10-letnia (2036): SYLION jest uznawaną globalnie infrastrukturą standardową dla organizacji wymagających suwerennego zarządzania komunikacją i pracą zdalną. Rdeń certyfikowalny jest open-source (certifiable open core model). Post-quantum PKI jest domyślnym stosem kryptograficznym. Tryb air-gap i wdrożenie sfederowane są produkcyjnie dojrzałe. Platforma obsługuje ponad 100 000 operatorów w wielu jurysdykcjach.

Rozdział 9. Cele strategiczne i kierunki rozwoju

9.1 Cele strategiczne: rdzeń certyfikowalny, suwerenność, ekosystem

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.1, 8.2, 8.7, 9.2, 9.5, 16.1

Strategia SYLION 3.0 opiera się na trzech filarach, które łącznie definiują unikalną pozycję platformy na rynku i determinują alokację zasobów w horyzoncie 5-letnim.

Filar 1: Rdzeń certyfikowalny (Certifiable Core). SYLION musi posiadać formalnie zdefiniowany i architektonicznie izolowany rdzeń systemu, który może przejść procesy certyfikacyjne bez wpływu na rozwój modułów autonomicznych. Rdzeń obejmuje: stos kryptograficzny (IPsec IKEv2, HSM/PKI), architekturę Split Gateway G1/G2, mechanizm izolacji workloadów (Firecracker microVM), kontrolę dostępu per-operator oraz infrastrukturę immutable. Wszystkie komponenty rdzenia muszą spełniać wymagania [N] Normatywny — każda zmiana w rdzeniu podlega Architecture Review Board i wymaga ponownej walidacji. Harmonogram certyfikacji: ISO 27001 Rok 1, FIPS 140-3 Rok 2, Common Criteria EAL4+ Rok 3.

Filar 2: Suwerenność technologiczna. Każdy klient musi mieć techniczną możliwość operowania platformą bez zależności od dostawcy SYLION (vendor lock-in), zagranicznego dostawcy chmurowego ani jakiegokolwiek strony trzeciej. Suwerenność obejmuje: (a) zdolność do wdrożenia on-premise lub w chmurze prywatnej; (b) lokalne zarządzanie kluczami kryptograficznymi (HSM on-premise); (c) kontrolę nad danymi rezydencji (data residency); (d) zdolność do operowania platformą siłami własnymi po transferze wiedzy. Suwerenność jest wzmocniona strukturą korporacyjną: Swiss AG jako główny podmiot prawny gwarantuje jurysdykcję sprzyjającą prywatności, bez ekspozycji na CLOUD Act. Kontrakty STATE sprzedawane są ze Szwajcarii lub USA, w zależności od jurysdykcji klienta i wymogów zamówień publicznych.

Filar 3: Ekosystem partnerski. SYLION nie może być monolitem kontrolowanym przez jedną organizację. Długoterminowa strategia wymaga ekosystemu certyfikowanych partnerów integracyjnych, technologicznych i compliance'owych. Partnerzy integracyjni wdrażają platformę u klientów, partnerzy technologiczni dostarczają komponenty (HSM, CDR, SIEM), a partnerzy compliance'owi wspierają procesy certyfikacyjne. Ekosystem redukuje ryzyko single-vendor i buduje zaufanie klientów sektora publicznego, którzy wymagają wieloźródłowości (multi-vendor strategy).

Trzy filary nie są niezależne — wzmacniają się wzajemnie. Certyfikowalny rdzeń ułatwia budowę ekosystemu (partnerzy mogą budować na stabilnym fundamencie). Suwerenność przyciąga klientów publicznych, których budżety finansują rozwój rdzenia. Ekosystem rozszerza zasięg rynkowy, generując przychody finansujące certyfikacje.

9.2 Cele biznesowe: przychody, udział w rynku, rentowność

Status: [N] Normatywny Odbiorca: Zarząd | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 9.1, 10.7, 10.8, 15.2, 16.1

Cele biznesowe SYLION 3.0 są zdefiniowane w trzech horyzontach czasowych, z konkretnymi metrykami mierzalnymi i powiązanymi z KPI opisanymi w Rozdziale 15.

Rok 1 — cel konserwatywny ~2 mln € ARR: - 50 operatorów na tierze STANDARD (400 €/operator/miesiąc) = 20 000 €/miesiąc = 240 000 € ARR - 20 operatorów na tierze PRO (1 500 €/operator/miesiąc) = 30 000 €/miesiąc = 360 000 € ARR - Pierwszy kontrakt STATE: 50 operatorów (od 2 500 €/operator/miesiąc) = 125 000 €/miesiąc = 1 500 000 € ARR - łączny cel ARR Roku 1: ~2 100 000 € - Sprzedaż hardware (100 zestawów startowych × 1 250 € jednorazowo) = 125 000 € przychodu jednorazowego - Przychody z professional services (wdrożenia, szkolenia): ~100 000–200 000 €

Rok 3 — cel ~10 mln € ARR: - 500 operatorów STANDARD: 200 000 €/miesiąc = 2 400 000 € ARR - 200 operatorów PRO: 300 000 €/miesiąc = 3 600 000 € ARR - 3 kontrakty STATE (łącznie 150 operatorów): 375 000 €/miesiąc = 4 500 000 € ARR - łączny cel ARR Roku 3: ~10 500 000 €

Horyzont długoterminowy (48–84 miesiące): Pozycja lidera rynku europejskiego, wejście na rynek północnoamerykański (z autoryzacją FedRAMP). Marża brutto powyżej 75% (charakterystyczna dla SaaS enterprise z niskim kosztem infrastruktury per-operator). LTV/CAC ratio powyżej 3:1. Cel: stać się domyślnym wyborem dla europejskich organizacji wymagających suwerennej, certyfikowalnej platformy komunikacji i pracy zdalnej.

Struktura przychodów w Roku 1 jest celowo zdominowana przez kontrakt STATE (~71% ARR). Jest to świadoma decyzja strategiczna — jeden kontrakt rządowy o wartości 1,5 mln €/rok stanowi solidną bazę finansową dla rozwoju, jednocześnie budując najcenniejszą referencję na rynku. Dywersyfikacja następuje w Roku 2–3 wraz ze wzrostem bazy klientów STANDARD i PRO.

9.3 Cele technologiczne: PQC, Confidential Computing, post-quantum PKI

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Dev | Infra Wpływ na baseline: Wysoki Powiązane rozdziały: 8.7, 9.1, 9.5, 12.13

Cele technologiczne SYLION 3.0 wykraczają poza dostarczenie funkcjonalnego produktu — obejmują budowę trwałej przewagi technologicznej, która będzie trudna do replikacji przez konkurencję.

Kryptografia post-kwantowa (PQC). Pojawienie się komputerów kwantowych zdolnych do łamania RSA i ECC jest kwestią czasu — estymacje NIST i NSA wskazują horyzont 2030–2035. SYLION musi być gotowy na tę tranzycję zanim stanie się pilna. Cel: do 2028 roku pełna obsługa algorytmów ML-KEM (Kyber) i ML-DSA (Dilithium) w warstwie transportowej (IPsec), warstwie komunikacyjnej (Matrix/MLS) i warstwie danych w spoczynku. Tranzycja musi być hybrydowa (classical + PQC) do czasu pełnej standaryzacji i dojrzałości implementacji.

Confidential Computing. AMD SEV-SNP i Intel TDX umożliwiają ochronę danych w trakcie przetwarzania (data-in-use) — uzupełniając tradycyjne szyfrowanie danych w spoczynku (at-rest) i w tranzycie (in-transit). Cel: do 2028 roku Confidential Computing jako baseline dla tieru STATE/SOVEREIGN. Implementacja musi obejmować transparentny opis ograniczeń: SEV-SNP posiada 49 CVE w historii (vs 9 dla TDX), w tym CVE-2024-56161 (podpisywanie mikro kodu) i atak Battering RAM (side-channel na cache). Confidential Computing jest warstwą defence-in-depth, lecz nie jest absolutną granicą bezpieczeństwa — komunikacja z klientami musi to odzwierciedlać. W analizie konkurencyjnej: Hypori nie posiada udokumentowanej ścieżki Confidential Computing — jest to wyróżnik SYLION w tierze STATE.

CVE-2025-29943 (StackWarp, marzec 2025). Atak na AMD SEV-SNP umożliwiający modyfikację stosu gościa z poziomu hypervisora, pozwalający na przejęcie kontroli nad VM mimo aktywnej ochrony pamięci. Razem z CVE-2024-56161 (podpisywanie mikro kodu) i atakami Battering RAM i Heracles, potwierdza, że Confidential Computing jest warstwą defence-in-depth, NIE absolutną granicą bezpieczeństwa. SYLION traktuje TEE jako jedną z wielu warstw ochrony, nie jako gwarancję nieprzeniknioności.

Post-quantum PKI. Pełna infrastruktura klucza publicznego oparta na algorytmach post-kwantowych: certyfikaty X.509 z PQC, łańcuchy zaufania PQC, HSM z obsługą PQC. Cel: do 2029 roku post-quantum PKI jako domyślny stos dla nowych wdrożeń.

Infrastruktura immutable. Wzmocnienie zasady „zniszcz i odbuduj zamiast łątać” — każdy komponent infrastruktury musi być odtwarzalny z Infrastructure as Code (IaC) w zdefiniowanym czasie. Cel: RTO < 30 minut dla odbudowy pełnego środowiska operatora z IaC. Koszt infrastruktury per-operator jest precyzyjnie kontrolowany: 3 instancje VPS (G1 gateway + G2 broker + VPS workload operatora) = $3 \times 20 \text{ €} = 60 \text{ €/operator/miesiąc}$, plus udział w strefie zarządzania $\sim 6 \text{ €/operator/miesiąc}$ = łączny koszt bazowy $\sim 66 \text{ €/operator/miesiąc}$. Ta kontrola kosztów zapewnia marżę brutto 79–94% w zależności od tieru.

9.4 Cele bezpieczeństwa: architektura zero-knowledge, gotowość audytowa

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.1, 8.3, 9.1, 9.5

Cele bezpieczeństwa SYLION 3.0 są zdefiniowane jako nienaruszalne właściwości systemu, których realizacja jest wymagana niezależnie od tieru wdrożeniowego, presji rynkowej czy ograniczeń budżetowych.

Zero-knowledge na terminalu. Terminal nie posiada żadnej wiedzy o danych, komunikacji ani tożsamości kryptograficznej operatora poza bieżącą sesją pikselową. Właściwość ta musi być weryfikowalna — audytor lub red team musi móc potwierdzić, że po zakończeniu sesji (lub fizycznym przejęciu terminala) nie istnieje materiał kryptograficzny, dane w spoczynku ani metadane sesji na urządzeniu.

Izolacja per-operator. Kompromitacja jednego operatora nie może prowadzić do kompromitacji innego operatora w tym samym tenancie lub w tym samym klastrze infrastruktury. Izolacja musi być egzekwowana na trzech poziomach: compute (oddzielne mikroVM Firecracker), sieć (mikrosegmentacja, VPC isolation), storage (oddzielne wolumeny z oddzielnymi kluczami szyfrowania). Każdy operator posiada dedykowane 3 instancje VPS (G1 + G2 + workload), co architektonicznie gwarantuje separację.

Gotowość audytowa ciągła. Platforma musi być w stanie gotowości audytowej w każdym momencie — nie tylko podczas przygotowań do certyfikacji. Oznacza to: kompletne logi audytowe (kto, co, kiedy, skąd — bez możliwości modyfikacji), zautomatyzowane testy compliance (CIS benchmarks, STIG, własne baseline checks), dokumentacja architektoniczna zawsze aktualna (niniejsza Księga), artefakty evidence automatycznie generowane (SBOM, scan results, access reviews).

Minimalizacja metadanych. System musi minimalizować metadane dostępne dla adversarza kontrolującego sieć: kto z kim komunikuje, kiedy, jak często, jak długo. Cel jest adresowany przez: kontrolę egress (cały ruch wychodzi przez zdefiniowane bramki G1/G2), stałe tunele IPsec (maskujące wzorce komunikacji), kontrolowaną federację Matrix (metadane nie wyciekają do zewnętrznych homeserverów), własny homeserver Matrix (zero zewnętrznych metadanych — przewaga, której Hypori nie posiada, będąc zależny od komercyjnej infrastruktury messagingowej).

9.5 Cele compliance: FIPS 140-3, Common Criteria, FedRAMP, ISO 27001

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 9.1, 9.3, 9.4, 14.9, 16.10

Certyfikacje i zgodności regulacyjne nie są „nice-to-have” — są warunkami dostępu do najbardziej wartościowych segmentów rynku. Klienci sektora publicznego, finansowego i obronnego wymagają udokumentowanej ścieżki certyfikacyjnej jako warunku kwalifikacji do przetargów i zakupów. Harmonogram certyfikacji jest kluczowym enablerem strategii Go-to-Market.

ISO 27001 — Rok 1 (2026–2027). Certyfikacja systemu zarządzania bezpieczeństwem informacji dla organizacji SYLION. ISO 27001 jest najszerzej uznawaną certyfikacją bezpieczeństwa w sektorze enterprise europejskim i stanowi minimum wymagane przez większość przetargów. Jest fundamentem, na którym budowane są kolejne certyfikacje. Realizacja w ramach Swiss AG.

FIPS 140-3 — Rok 2 (2027–2028). Wszystkie moduły kryptograficzne SYLION — w tym implementacje IPsec IKEv2, zarządzanie kluczami HSM, szyfrowanie danych w spoczynku — muszą używać implementacji walidowanych FIPS 140-3 lub być na udokumentowanej ścieżce do walidacji. Wymagany poziom: minimum Level 2 dla tieru PRO, Level 3 dla tieru STATE/SOVEREIGN (HSM fizyczny). Wybór IPsec IKEv2 zamiast WireGuard jest bezpośrednią konsekwencją tego celu — WireGuard nie posiada walidacji FIPS i nie jest na ścieżce walidacji.

Common Criteria EAL4+ — Rok 3 (2028–2029). Rdzeń certyfikowalny SYLION musi przejść ewaluację Common Criteria na poziomie EAL4+ z augmentacjami ALC_FLR.3 i AVA_VAN.5. Common Criteria jest warunkiem wejścia do segmentu government i defence-adjacent.

FedRAMP High — Rok 4+ (2029+). Autoryzacja FedRAMP High jest warunkiem dostępu do rynku federalnego USA. Model referencyjny: Hypori — osiągnął FedRAMP High Authorization w marcu 2025. Realizacja przez US LLC/Corp. FedRAMP wymaga wdrożenia w środowisku autoryzowanym (AWS GovCloud, Azure Government) i 325 kontroli bezpieczeństwa z NIST SP 800-53 High.

Dodatkowe zgodności: CNSA 2.0 (NSA suite algorytmów kryptograficznych — konieczne dla rynku obronnego), NIS2 (dyrektywa UE), DORA (sektor finansowy), RODO/GDPR (data residency, minimalizacja danych).

9.6 Cele operacyjne: dostępność, RTO, niezawodność

Status: [N] Normatywny Odbiorca: Zarząd | Infra | SOC | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 9.1, 15.5, 15.6

Platforma bezpiecznej komunikacji i pracy zdalnej jest użyteczna wyłącznie wtedy, gdy jest dostępna. SYLION 3.0 definiuje cele operacyjne, które muszą być zagwarantowane w umowach SLA z klientami i monitorowane w trybie ciągłym.

Dostępność (uptime). Cel: 99,95% dostępności usługi mierzonej jako procent czasu w miesiącu, w którym operator może nawiązać i utrzymać sesję roboczą. 99,95% oznacza maksymalnie ~22 minuty niedostępności miesięcznie. Dla tieru STATE/SOVEREIGN cel powinien wynosić 99,95% (< 4,3 minuty miesięcznie) z architekturą multi-region active-active.

RTO (Recovery Time Objective). Cel: < 4 godziny dla pełnego odtworzenia usługi po katastrofalnej awarii regionu. Dla odbudowy pojedynczego środowiska operatora z laC: < 30 minut. Dla przełączenia na region zapasowy (failover): < 15 minut.

RPO (Recovery Point Objective). Cel: < 1 godzina utraty danych dla danych komunikacyjnych (Matrix history), < 15 minut dla danych konfiguracyjnych (operator profiles, access policies).

Latencja sesji. Cel: < 100 ms latencji end-to-end dla interakcji pikselowej (input-to-display). Latencja powyżej 150 ms degraduje doświadczenie użytkownika do poziomu frustracji.

Provisionowanie operatora. Cel: < 15 minut od zatwierdzenia przez admina do gotowości środowiska operatora do pracy. Pełna automatyzacja: laC → 3 instancje VPS (G1 + G2 + workload, łączny koszt 60 €/miesiąc) → konfiguracja sieci → workloady → testy zdrowotności → gotowość.

9.7 Cele rynkowe: segmenty docelowe i priorytety

Status: [N] Normatywny Odbiorca: Zarząd | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 9.1, 9.2, 11.1, 16.1

Strategia rynkowa SYLION 3.0 jest zdefiniowana jako trójfazowa ekspansja, determinowana przez: (a) natychmiastowość potrzeby, (b) gotowość do zapłacenia premium, (c) brak złożonego cyklu zamówień, (d) zdolność do generowania referencji dla kolejnych segmentów.

Faza 1 — Europa (startuje teraz). Pięć segmentów docelowych uruchamianych równolegle:

Kancelarie prawne — poufność klienta, GDPR, wysokie ryzyko ataków celowanych, wysoka gotowość do zapłacenia. Tajemnica adwokacka jest prawnie chroniona — naruszenie generuje bezpośrednie konsekwencje prawne i finansowe. Tier docelowy: STANDARD/PRO.

Dziennikarze śledczy — ochrona źródeł, aktorzy państwowi jako adwersarze, zbieżność z misją Freedom of Press Foundation. Segment budujący reputację marki. Tier docelowy: PRO.

Politycy opozycji i osoby publiczne — aktywne ryzyko inwigilacji, celowanie przez obce wywiady, brak złożoności zamówień rządowych (klienci prywatni). Tier docelowy: PRO, sprzedaż ze Szwajcarii.

NGO i organizacje praw człowieka operujące w wrogich środowiskach. Tier docelowy: PRO.

Kadra zarządzająca korporacji o wysokim profilu ryzyka — M&A, aktywizm inwestorski, członkowie zarządów. Tier docelowy: PRO.

Dlaczego te segmenty w Fazie 1: Mają natychmiastową potrzebę (nie „kiedyś przydałoby się”, lecz „potrzebuję tego teraz”). Posiadają wysoką gotowość do zapłacenia premium. Nie wymagają złożonych cykli zamówień publicznych. Stanowią najlepsze referencje dla późniejszej sprzedaży enterprise/government — jeśli SYLION chroni dziennikarza śledczego przed Pegasusem, argument dla CISO korporacji jest oczywisty. Budują wiarygodność na najtrudniejszych przypadkach użycia.

Faza 2 — Obronność i rząd (po certyfikacjach). Po uzyskaniu ISO 27001, na ścieżce FIPS 140-3: kontrahenci wojskowi, konsultanci obronni, biura bezpieczeństwa parlamentarnego, narodowe agencje cyberbezpieczeństwa, ministerstwa spraw zagranicznych. Tier STATE, minimum 50 operatorów = minimum 125 000 €/miesiąc = 1,5 mln €/rok per klient.

Faza 3 — Rynek USA. Wejście przez istniejące europejskie referencje. Kancelarie prawne US, dziennikarze US. FedRAMP jako cel długoterminowy (2–3 lata po wejściu europejskim). Sprzedaż przez US LLC/Corp z partnerem US-based MSSP.

9.8 Cele partnerskie: integratorzy, audytorzy, dostawcy technologii

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Średni Powiązane rozdziały: 9.1, 10.6, 16.5, 16.9

Strategia partnerska SYLION 3.0 ma na celu budowę ekosystemu, który zmniejsza ryzyko single-vendor dla klientów i rozszerza zasięg rynkowy platformy.

Partnerzy integracyjni (system integrators). Firmy wdrożeniowe posiadające kompetencje infrastrukturalne, bezpieczeństwa i compliance. Role: wdrożenie platformy u klienta, migracja z istniejących rozwiązań, szkolenie personelu, wsparcie operacyjne Tier 1. Model: certyfikacja partnera przez SYLION (szkolenie techniczne, egzamin, audyt wdrożenia referencyjnego). Cel: 5 certyfikowanych integratorów do końca 2027, 10+ do końca 2029. Revenue share: partner uzyskuje marżę na kontrakcie klienta (model reseller lub referral fee).

Partnerzy technologiczni. Dostawcy komponentów integrowanych z platformą SYLION: (a) dostawcy HSM (Thales, Entrust, Utimaco); (b) dostawcy CDR (Votiro, OPSWAT, Glasswall); (c) dostawcy SIEM/SOAR (Splunk, Elastic, Sentinel); (d) dostawcy chmurowi (AWS, Azure, OVHcloud, Hetzner); (e) ekosystem Matrix (Element, Beeper).

Partnerzy compliance i audytowi. Firmy audytorskie zdolne do przeprowadzenia certyfikacji: Big 4 dla procesów ISO 27001, laboratoria Common Criteria (BSI w Niemczech, ANSSI we Francji, CCN w Hiszpanii), laboratoria FIPS (NIST CMVP). Cel: utrzymanie stałej relacji z minimum 2 laboratoriami certyfikacyjnymi.

US-based MSSP partner. Kluczowy partner dla Fazy 3 (rynek USA). Partner z doświadczeniem FedRAMP, istniejącymi relacjami z kancelariami prawniczymi, mediami i instytucjami federalnymi USA. Model: dystrybucja SYLION na rynku USA, wsparcie w procesie FedRAMP, lokalne wsparcie klienta.

9.9 Strategia długoterminowej suwerenności i niezależności technologicznej

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 9.1, 9.3, 9.5, 16.10

Suwerenność technologiczna jest celem strategicznym SYLION 3.0 na dwóch poziomach: suwerenność klienta (klient może operować platformą niezależnie) oraz suwerenność platformy (SYLION jako organizacja minimalizuje zależności od dostawców).

Suwerenność klienta jest adresowana przez: (a) pełna dokumentacja architektoniczna i operacyjna (niniejsza Księga, runbooki, IaC); (b) transfer wiedzy jako element wdrożenia; (c) architektura umożliwiająca wdrożenie na dowolnej infrastrukturze; (d) lokalne zarządzanie kluczami (HSM on-premise); (e) kod rdzenia certyfikowalnego potencjalnie open-source w perspektywie 10-letniej.

Suwerenność platformy wymaga zarządzania zależnościami technologicznymi: (a) Firecracker (open-source, Apache 2.0 — niskie ryzyko vendor lock-in); (b) Matrix (open-source, Apache 2.0 — kontrola nad homeserverem); (c) IPsec IKEv2 (standard IETF, wiele implementacji — brak vendor lock-in); (d) AMD SEV-SNP / Intel TDX (zależność od dwóch dostawców CPU — ryzyko akceptowalne przy dual-vendor strategy); (e) GrapheneOS (open-source, community-driven — ryzyko umiarkowane, uzależnienie od hardware Google Pixel).

Ryzyko GrapheneOS-Pixel: Jedynym wspieranym hardware dla GrapheneOS są telefony Google Pixel. Zależność od jednego producenta hardware jest zidentyfikowanym ryzykiem. Mitygacja: (a) pakiet hardware'owy SYLION bazuje na najnowszym dostępnym modelu Pixel (aktualnie ~900 €), lecz architektura terminala jako „wymienialny komponent” oznacza, że zmiana hardware nie wymaga migracji danych; (b) zarządzany laptop jako alternatywny terminal; (c) monitorowanie alternatywnych projektów secure Android.

Suwerenność korporacyjna: Trójstruktura korporacyjna SYLION (Swiss AG → US LLC/Corp → Polish Sp. z o.o.) jest zaprojektowana z myślą o suwerenności jurysdykcyjnej. Swiss AG jako podmiot centralny minimalizuje ekspozycję na jurysdykcję z mechanizmami przymusowego dostępu do danych. Klienci prywatni (osoby fizyczne, dziennikarze, politycy, NGO) obsługiwani wyłącznie ze Szwajcarii lub USA.

Rozdział 10. Propozycja wartości i model biznesowy

10.1 Główna propozycja wartości

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.1, 8.2, 8.3, 10.2, 12.13

Dane rynkowe (research kwiecień 2026). Globalny TAM dla konwergentnego rynku bezpiecznych workspace'ów (secure communications + Zero Trust + VDI + SASE) szacowany na \$80–120 miliardów w 2025, z europejskim udziałem \$20–30 miliardów. Wzrost 15–20% CAGR. Kluczowe segmenty: enterprise secure communications \$7.41B (CAGR 21.7%), Zero Trust \$41.7B (CAGR 14.8–16.6%), VDI/DaaS \$19.26B (CAGR 22.1%). Europejskie budżety obronne osiągnęły €381 miliardów w 2025 (wzrost 20% YoY wg NATO/Bloomberg), z nowym celem 3.5% PKB uzgodnionym na szczycie w Hadze. Europejski rynek defense electronics: \$25.6B w 2025. GDPR: €1.2 miliarda kar w 2025, 443 zgłoszenia naruszeń dziennie (wzrost 22% YoY, DLA Piper 2026).

„Kompromitacja terminala ≠ kompromitacja danych.”

Jedno zdanie, które definiuje fundamentalną wartość SYLION 3.0 dla każdego klienta, niezależnie od segmentu, tieru wdrożeniowego i modelu zagrożeń. Propozycja wartości jest rozwinięta w pięciu wymiarach bezpieczeństwa:

Bezpieczeństwo fizyczne. Skradziony, zgubiony lub skonfiskowany terminal nie zawiera żadnych danych biznesowych, kluczy kryptograficznych ani historii komunikacji. Adwersarz uzyskujący fizyczny dostęp do urządzenia pozyskuje wyłącznie sprzęt z systemem operacyjnym — nawet zaawansowana analiza forensyczna (chip-off, JTAG, cold boot) nie ujawni danych, ponieważ nigdy nie zostały one zapisane na urządzeniu.

Bezpieczeństwo prawne. Serwer przejęty na mocy nakazu sądowego zawiera wyłącznie zaszyfrowane dane operatorów, z kluczami zarządzanymi przez HSM niezależny od serwera. W konfiguracji suwerennej (tier STATE/SOVEREIGN) klucze HSM rezydują fizycznie u klienta — nawet przejęcie infrastruktury chmurowej nie daje dostępu do materiału kryptograficznego. Swiss AG jako podmiot prawny oznacza jurysdykcję sprzyjającą prywatności, bez ekspozycji na CLOUD Act.

Bezpieczeństwo operacyjne. Zainfekowany terminal — nawet exploitem klasy Pegasus — widzi wyłącznie strumień pikselowy bieżącej sesji. Nie ma dostępu do danych w spoczynku (nie istnieją na terminalu), kluczy (rezydują w HSM/VPS), pełnej historii komunikacji (nie jest cachowana) ani danych uwierzytelniających (MFA + FIDO2 biometric key + asymmetric auth).

Bezpieczeństwo insiderowe. Operator widzi wyłącznie autoryzowany workspace — środowiska, do których został uprawniony. Mikrosegmentacja per-operator oznacza, że insider nie może przejść lateralnie do środowisk innych operatorów. Każda akcja jest logowana w immutable audit log.

Bezpieczeństwo lateralne. Kompromitacja jednego operatora nie oznacza kompromitacji pozostałych operatorów. Izolacja per-operator na poziomie compute (oddzielne mikroVM), sieci (mikrosegmentacja, Split Gateway G1/G2) i storage (oddzielne klucze) — każdy operator operuje na 3 dedykowanych instancjach VPS.

10.2 Wartość dla kancelarii prawnych i sektora prawnego

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 10.1, 11.2, 13.1, 14.1

Kancelarie prawne stanowią priorytetowy segment Fazy 1 GTM z trzech powodów: tajemnica adwokacka tworzy prawny obowiązek ochrony danych, ryzyko ataków celowanych jest wysokie (kancelarie obsługujące M&A, sprawy antytrustowe, spory korporacyjne), a gotowość do zapłacenia premium jest wśród najwyższych w sektorze komercyjnym.

Wartość dla kancelarii: - Tajemnica adwokacka (legal privilege): SYLION architektonicznie gwarantuje, że nawet w przypadku fizycznego przejęcia urządzenia partnera lub prawnika, konfiskata nie ujawni komunikacji z klientem. W jurysdykcjach common law (UK, USA) naruszenie legal privilege może prowadzić do dyskwalifikacji dowodów — SYLION zapewnia techniczny fundament tej ochrony. - Data room M&A: Izolowane środowisko env-office dla transakcji M&A, z CDR na wejściu/wyjściu dokumentów, audit trail rejestrujący każde otwarcie dokumentu. Wyciek planu przejęcia może kosztować setki milionów — roczny koszt SYLION PRO dla 20 prawników to 360 000 € (20 × 1 500 € × 12), ułamek potencjalnej straty. - Compliance GDPR/RODO: Automatyczne generowanie artefaktów compliance — audit logi, raporty dostępu, inwentaryzacja aktywów. Kancelaria demonstruje regulatorowi (UODO/ICO/CNIL), że dane Klientów są chronione adekwatnie.

Kalkulacja wartości: Średni koszt naruszenia danych w sektorze prawnym to 4,7 mln USD (IBM Cost of a Data Breach 2025). Roczny koszt SYLION STANDARD dla 50-osobowej kancelarii to 240 000 € (50 × 400 € × 12). SYLION jest tańszy niż jeden poważny incydent — o rząd wielkości.

10.3 Wartość dla dziennikarzy, polityków i organizacji wysokiego ryzyka

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 10.1, 10.5, 11.3, 11.4, 13.13

Dziennikarze śledczy, politycy opozycji, działacze praw człowieka i NGO operujące w wrogich środowiskach — to segmenty, w których adwersarzem jest państwo lub aktor state-sponsored, a stawka jest bezpieczeństwo osobiste, ochrona źródeł i wolność słowa.

Wartość dla dziennikarzy śledczych: - Ochrona źródeł: Terminal SYLION przekraczający granicę państwa autorytarne nie zawiera żadnych danych — kontrola graniczna, forensic analysis urządzenia nie ujawni źródeł, kontaktów ani komunikacji. Dla dziennikarza Bellingcat, OCCRP, Forbidden Stories — to różnica między bezpieczeństwem a zagrożeniem życia. - Odporność na Pegasus: Nawet jeśli terminal zostanie zainfekowany, adversarz uzyskuje dostęp wyłącznie do bieżącego strumienia pikselowego. Nie uzyskuje historii komunikacji, listy kontaktów, archiwum dokumentów — dane te nie istnieją na terminalu. - Sprzedaż ze Szwajcarii: Kontrakty z klientami prywatnymi (dziennikarze, politycy, NGO) realizowane wyłącznie przez Swiss AG lub US LLC — jurysdykcje z silną ochroną prywatności.

Wartość dla polityków opozycji: - Aktywne ryzyko inwigilacji: Politycy opozycji są celem inwigilacji przez obce służby i nierzadko przez służby własnego państwa. SYLION eliminuje endpoint jako wektor — nawet kompromitacja telefonu nie daje dostępu do komunikacji. - Brak złożoności zamówień publicznych: Politycy jako osoby prywatne mogą kupić subskrypcję PRO bezpośrednio, bez przetargów, komisji i procedur.

Wartość strategiczna segmentu: Niski bezpośredni przychód (kilkadziesiąt subskrypcji PRO), lecz bardzo wysoka wartość reputacyjna. Endorsement ze strony uznanego dziennikarza śledczego lub organizacji wolnoprasowej jest wart wielokrotność kosztów subsydiowania. Segment ten buduje narrative: „SYLION chroni tych, którzy chronią prawdę” — najsilniejszy element brand storytelling, otwierający drzwi do kolejnych segmentów.

10.4 Wartość dla sektora publicznego i defence-adjacent

Status: [R] Rekomendowany Odbiorca: Zarząd | Compliance | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 10.1, 11.5, 14.9, 16.10

Sektor publiczny — ministerstwa, agencje rządowe, parlamenty, podmioty obronno-przemysłowe — posiada wymagania fundamentalnie odmienne od enterprise: suwerenność nie jest preferencją, lecz wymogiem bezwzględny. Segment ten jest adresowany w Fazie 2 GTM, po uzyskaniu certyfikacji.

Suwerenne wdrożenie bez zależności zagranicznej. SYLION tier STATE/SOVEREIGN (od 2 500 €/operator/miesiąc, minimum 50 operatorów) może być wdrożony w całości na infrastrukturze krajowej: serwery w krajowych centrach danych, HSM w siedzibie klienta, zarządzanie kluczami przez krajowy zespół. Minimalny kontrakt: 50 operatorów × 2 500 € = 125 000 €/miesiąc = 1,5 mln €/rok — obejmuje profesjonalne usługi wdrożeniowe i adaptację funkcjonalną (custom implementation).

Ścieżka certyfikacyjna uznawana przez regulatorów krajowych. ISO 27001 Rok 1 → FIPS 140-3 Rok 2 → Common Criteria EAL4+ Rok 3. Posiadanie udokumentowanej ścieżki certyfikacyjnej jest warunkiem kwalifikacji do przetargów publicznych. Kontrakty STATE sprzedawane ze Szwajcarii lub USA, w zależności od jurysdykcji klienta.

Redukcja kosztów sprzętu dedykowanego. Tradycyjne podejście wymaga wydawania dedykowanych, zahartowanych urządzeń — kosztowne i logistycznie skomplikowane. SYLION z modelem Thin Client umożliwia użycie standardowego zestawu hardware'owego (Pixel + router + FIDO2 key = 1 250 € jednorazowo per operator) zamiast terminali za kilkanaście tysięcy euro.

10.5 Wartość dla enterprise klasycznego i regulowanego

Status: [R] Rekomendowany Odbiorca: Zarząd | Compliance | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 10.1, 10.2, 11.2, 14.1

Dla klientów enterprise klasycznych SYLION 3.0 dostarcza wartość w czterech wymiarach: suwerenność danych, zgodność regulacyjna, ochrona własności intelektualnej i ochrona przed zagrożeniami insiderskimi.

Suwerenność danych jest kluczowa dla organizacji operujących w wielu jurysdykcjach. SYLION zapewnia pełną kontrolę nad lokalizacją danych (data residency), eliminując ryzyko ekstraterytorialnego dostępu (np. US CLOUD Act wobec danych europejskich przechowywanych u amerykańskiego dostawcy chmurowego). Swiss AG jako podmiot prawny gwarantuje europejską jurysdykcję wolną od CLOUD Act.

Zgodność regulacyjna jest coraz częściej warunkiem prowadzenia działalności, nie opcjonalnym dodatkiem. SYLION wspiera klientów w spełnieniu wymagań NIS2, DORA, RODO/GDPR oraz regulacji sektorowych. Architektura SYLION generuje artefakty compliance automatycznie.

Ochrona własności intelektualnej. M&A teams, zespoły R&D, zarządy — grupy pracujące z informacjami o najwyższej wrażliwości biznesowej. Wyciek planu przejścia, formuły produktu czy strategii cenowej może kosztować setki milionów. Roczny koszt SYLION PRO dla 10-osobowego zarządu to 180 000 € (10 × 1 500 € × 12) — ułamek potencjalnej straty z wycieku.

Ochrona przed insider threat. Według raportu IBM Cost of a Data Breach 2025, koszty incydentów spowodowanych przez złośliwych insiderów wynoszą średnio 4,92 mln USD. SYLION redukuje powierzchnię insiderską: operator widzi tylko autoryzowane środowiska, nie może eksportować danych bez CDR, każda akcja jest logowana.

10.6 Wartość dla partnerów integracyjnych

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Niski Powiązane rozdziały: 9.8, 10.7, 16.5, 16.9

Partnerzy integracyjni — system integratorzy, MSSPy, konsultanci compliance — stanowią kluczowy kanał dystrybucji SYLION 3.0 i jednocześnie są beneficjentami ekosystemu platformy.

SDK i API. SYLION udostępnia partnerom SDK umożliwiającą budowę niestandardowych integracji: łączenie SYLION z istniejącą infrastrukturą klienta (SIEM, IAM, ITSM), automatyzacja provisioningu operatorów, budowa dashboardów zarządczych.

Program certyfikowanego integratora. Trzy poziomy certyfikacji: Bronze (wdrożenie STANDARD), Silver (wdrożenie PRO + compliance support), Gold (wdrożenie STATE/SOVEREIGN + red team capability). Każdy poziom daje dostęp do odpowiedniego tieru klientów i odpowiedni poziom marży. Dla partnera wdrażającego kontrakt STATE (minimum 1,5 mln €/rok per klient) — marża partnera jest ekonomicznie atrakcyjna od pierwszego wdrożenia.

10.7 Model przychodowy

Status: [N] Normatywny Odbiorca: Zarząd | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 10.1, 10.8, 10.9, 14.1, 15.2

Model przychodowy SYLION 3.0 łączy cztery główne strumienie przychodów:

Strumień 1: Subskrypcja per-operator per-miesiąc (primary — ~85% ARR docelowo). Główne źródło przychodów. Opłata subskrypcyjna za każdego aktywnego operatora, różnicowana według tieru: - STANDARD: 400 €/operator/miesiąc, subskrypcje 6 lub 12 miesięcy - PRO: 1 500 €/operator/miesiąc, subskrypcja wyłącznie

12 miesięcy - STATE/SOVEREIGN: od 2 500 €/operator/miesiąc, minimum 50 operatorów, obejmuje usługi wdrożeniowe i adaptację funkcjonalną (custom implementation)

Brak minimalnej liczby operatorów dla tierów STANDARD i PRO — umożliwia to sprzedaż pojedynczym dziennikarzom, politykom i małym kancelariom.

Strumień 2: Sprzedaż pakietów hardware’owych (jednorazowy — ~5% przychodów). Pakiet hardware’owy sprzedawany oddzielnie od subskrypcji: - GL-iNet Beryl AX (MT-3000) router lub równoważny router podróżny z obsługą OpenWrt + IPsec IKEv2: 150 € - Google Pixel (najnowszy dostępny model): 900 € - Biometryczny klucz FIDO2 (np. Yubico YubiKey Bio): 200 € - łączny pakiet startowy: 1 250 € per operator (jednorazowo)

Starlink: operator może pozyskać niezależnie (nie jest częścią pakietu). Cel Roku 1: 100 zestawów startowych = 125 000 € przychodu jednorazowego.

Strumień 3: Usługi profesjonalne (~5–8% przychodów). Wdrożenie i migracja, szkolenia, red team/pentest, consulting compliance. Marża ~60%. Szczególnie istotne dla kontraktów STATE, gdzie usługi wdrożeniowe są wliczone w cenę subskrypcji.

Strumień 4: Moduły dodatkowe. Matrix homeserver (opcjonalny add-on): +20 €/operator/miesiąc dodawane do ceny subskrypcji. PQC Module, Confidential Computing, Dark-Matrix — wyceniane odrębnie.

10.8 Struktura kosztów infrastrukturalnych

Status: [N] Normatywny Odbiorca: Zarząd Wpływ na baseline: Wysoki Powiązane rozdziały: 10.7, 10.9, 10.11, 15.2

Struktura kosztów infrastrukturalnych SYLION jest precyzyjnie kontrolowana i stanowi fundament kalkulacji marży.

Koszty infrastrukturalne per-operator (strona kosztowa):

Komponent	Koszt miesięczny
G1 gateway VPS	20 €
G2 broker VPS	20 €
VPS workload operatora	20 €
Łącznie 3 instancje VPS	60 €/operator/miesiąc
Strefa zarządzania (shared, ~10% per operator)	~6 €/operator/miesiąc
Łączny koszt bazowy per operator	~66 €/miesiąc
Matrix homeserver (opcjonalny add-on)	+20 €/operator/miesiąc
Łączny koszt z Matrix	~86 €/miesiąc

Architektura 3 dedykowanych instancji VPS per operator (G1 + G2 + workload) nie jest nadmiarowa — jest fundamentem izolacji. G1 gateway obsługuje terminację tunelu IPsec, G2 broker zarządza dostępem do workloadu, VPS workload operatora hostuje izolowane środowiska pracy. Separacja ta zapewnia defence-in-depth: kompromitacja jednego komponentu nie daje automatycznego dostępu do pozostałych.

Koszty ludzkie (skalujące się): - SOC: 1 analityk per ~200 operatorów - SRE: 1 inżynier per ~500 operatorów - Compliance: zespół o stałej wielkości, rosnący skokowo przy nowych certyfikacjach - Wsparcie klienta: zależne od tieru (STATE wymaga dedykowanego support) - Development: zespół bazowy w polskiej Sp. z o.o. (operational entity)

Koszty certyfikacyjne (jednorazowe, amortyzowane): - FIPS 140-3 walidacja: ~200–500 tys. USD - Common Criteria ewaluacja: ~300–800 tys. USD - FedRAMP autoryzacja: ~1–3 mln USD z 3PAO assessment - ISO 27001: ~50–150 tys. USD

10.9 Analiza marży per tier

Status: [N] Normatywny Odbiorca: Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 10.7, 10.8, 10.11, 15.2

Analiza marży brutto per tier, przed kosztami ludzkimi, demonstruje ekonomiczną atrakcyjność modelu SYLION na każdym poziomie cenowym:

Zaktualizowany model kosztowy z uwzględnieniem ukrytych kosztów:

Składnik	STANDARD	PRO	STATE
3x VPS (G1+G2+Operator)	€60	€60	€80 (dedicated)
Management zone share	€6 (przy 50+ op.)	€6	€10 (dedicated)
Matrix homeserver	€20	€20	€20
SIEM/Monitoring share	€5	€5	€10 (dedicated)
CDR (open-source/OPSWAT)	€0 (DocBleach)	€20 (OPSWAT share)	€30 (OPSWAT dedicated)
HSM share	€0	€5 (CloudHSM)	€15 (dedicated Luna)
Backup/DR	€3	€5	€10
ŁĄCZNY koszt infra	€94	€121	€175
Cena subskrypcji	€400	€1 500	€2 500
Marża brutto	€306 (77%)	€1 379 (92%)	€2 325 (93%)

Marże pozostają zdrowe (77–93%) nawet po uwzględnieniu ukrytych kosztów. Kluczowa różnica vs poprzednia kalkulacja: STANDARD marża spada z 79% do 77%, PRO z 94% do 92%.

STANDARD (400 €/operator/miesiąc):

Element	Wartość
Przychód per operator	400 €
Koszt infrastruktury (bez Matrix)	~66 €
Koszt infrastruktury (z Matrix)	~86 €
Marża brutto (bez Matrix)	334 € = ~84%
Marża brutto (z Matrix)	314 € = ~79%

Marża 79–84% przed kosztami ludzkimi jest charakterystyczna dla najlepszych modeli SaaS. Przy 50 operatorach STANDARD (cel Roku 1) marża brutto wynosi 15 700–16 700 €/miesiąc z samych subskrypcji.

PRO (1 500 €/operator/miesiąc):

Element	Wartość
Przychód per operator	1 500 €
Koszt infrastruktury (Matrix wliczony, więcej compute dla mikroVM)	~86 €
Marża brutto	1 414 € = ~94%

Marża 94% odzwierciedla premium pricing za zaawansowane funkcje bezpieczeństwa, rozszerzony monitoring SOC i szybszy SLA wsparcia. Przy 20 operatorach PRO (cel Roku 1) marża brutto wynosi 28 280 €/miesiąc.

STATE/SOVEREIGN (od 2 500 €/operator/miesiąc, minimum 50 operatorów):

Element	Wartość
Przychód per operator	od 2 500 €
Koszt infrastruktury (dedykowany hardware, więcej compute)	~100–120 €
Komponent professional services (wliczony w cenę)	~200–400 € (alokacja)
Marża brutto (na infrastrukturze)	~2 000–2 200 € = ~80–88%
Marża po alokacji services	~70–80%
Minimalny kontrakt	50 × 2 500 € = 125 000 €/miesiąc = 1,5 mln €/rok

Kontrakt STATE o wartości 1,5 mln €/rok przy marży brutto 70–80% generuje 1,05–1,2 mln € marży brutto rocznie — wystarczające do sfinansowania znacznej części zespołu development i compliance.

Porównanie marż z benchmarkiem branżowym:

Tier	Marża brutto SYLION	Benchmark SaaS B2B	Komentarz
STANDARD	79–84%	65–75%	Powyżej benchmarku — niski koszt infrastruktury
PRO	~94%	70–80%	Znacząco powyżej — premium pricing
STATE	70–80%	55–65%	Powyżej — mimo usług wliczonych

Wysoka marża brutto jest konsekwencją dwóch czynników: (1) koszt infrastruktury per-operator (66–120 €) jest relatywnie niski wobec ceny (400–2 500+ €); (2) model per-operator z 3 dedykowanymi VPS zapewnia transparentną i przewidywalną strukturę kosztów.

10.10 Koszt wdrożenia vs koszt incydentu

Status: [R] Rekomendowany Odbiorca: Zarząd | Compliance | Klient Wpływ na baseline: Średni Powiązane rozdziały: 10.1, 10.7, 10.11, 15.2

Kalkulacja wartości SYLION 3.0 musi być osadzona w kontekście realnych kosztów incydentów bezpieczeństwa — ponieważ platforma nie jest kosztem, lecz ubezpieczeniem przed stratami wielokrotnie przewyższającymi inwestycję.

Średni koszt naruszenia danych (IBM Cost of a Data Breach Report 2025): globalnie 4,44 mln USD, w USA 10,22 mln USD, w sektorze ochrony zdrowia 7,42 mln USD. Incydenty spowodowane przez złośliwych insiderów: średnio 4,92 mln USD.

Kalkulacja porównawcza — kancelaria prawna (50 operatorów, tier STANDARD):

Element	Wartość
Roczny koszt subskrypcji	50 × 400 € × 12 = 240 000 €
Pakiet hardware (jednorazowy)	50 × 1 250 € = 62 500 €
Koszt Year 1 (subskrypcja + hardware)	302 500 €
Średni koszt jednego incydentu	~4 100 000 € (4,44 mln USD)
Stosunek koszt SYLION / koszt incydentu	~7,4%

SYLION kosztuje 7,4% średniego kosztu jednego incydentu. Przy założeniu, że SYLION redukuje prawdopodobieństwo incydentu naruszenia danych z endpointów o 80–95% (dzięki eliminacji danych na terminalu), Expected Annual Loss jest redukowany o wielokrotność rocznego kosztu platformy.

Kalkulacja porównawcza vs Hypori pricing:

Hypori nie publikuje transparentnego cennika. Dostępne źródła wskazują na model porównywalny lub wyższy cenowo, z ograniczeniem do jurysdykcji US (AWS GovCloud). SYLION oferuje: - Transparentne europejskie ceny (400/1 500/2 500+ €) - Brak wymogu AWS GovCloud (multi-cloud, on-premise) - Pełna platforma pracy (nie tylko mobile messaging) - Hardware starter kit (Hypori nie oferuje — operator musi sam zapewnić endpointy)

10.11 ROI i TCO

Status: [R] Rekomendowany Odbiorca: Zarząd | Compliance | Klient Wpływ na baseline: Średni Powiązane rozdziały: 10.7, 10.8, 10.10, 15.2

Pięcioletnie porównanie TCO (Total Cost of Ownership) SYLION 3.0 vs tradycyjny stos MDM + VPN + endpoint security dla 50-osobowej kancelarii prawnej:

Tradycyjny stos (50 operatorów, 5 lat):

Komponent	Roczny koszt (szacunkowy)
MDM (Intune/Jamf)	50 × 12 € × 12 = 7 200 €
VPN enterprise (Cisco/Palo Alto)	50 × 15 € × 12 = 9 000 €
Endpoint security (CrowdStrike)	50 × 20 € × 12 = 12 000 €
Secure messaging (Threema Work)	50 × 5 € × 12 = 3 000 €
DLP (Symantec/Forcepoint)	50 × 10 € × 12 = 6 000 €
Dedykowane urządzenia (amort.)	50 × 400 € = 20 000 €
Personel (partial FTE: admin)	~40 000 €
Roczny TCO (bez incydentów)	~97 200 €
Expected Annual Loss (2% × 4,44M USD)	~81 700 €
Roczny TCO (z EAL)	~178 900 €
5-letni TCO	~894 500 €

SYLION STANDARD (50 operatorów, 5 lat):

Komponent	Roczny koszt
Subskrypcja (50 × 400 € × 12)	240 000 €
Hardware Y1 + refresh Y3 (50 × 1 250 €)	62 500 € × 2 = 125 000 € (5 lat)
Szkolenie	10 000 €
EAL (zredukowane o 85%)	~12 250 €
Roczny TCO (bez hardware amort.)	~252 250 €
5-letni TCO	~1 261 250 €

TCO SYLION jest wyższe niż tradycyjny stos w kwotach bezwzględnych (~1,26 mln € vs ~0,89 mln €). Jednak kluczowa różnica leży w profilu ryzyka: tradycyjny stos pozostawia dane na endpointzie i jest podatny na klasy ataków, które SYLION eliminuje architektonicznie. Dla kancelarii prawnej, gdzie jeden incydent naruszenia tajemnicy adwokackiej może kosztować reputację i klientów — ROI z SYLION jest niepoliczalny.

Argument sprzedażowy nie brzmi „SYLION jest tańszy” — brzmi „SYLION jest tańszy niż jeden incydent, a tradycyjny stos nie chroni przed incydemem klasy Pegasus/konfiskata”.

10.12 Struktura korporacyjna i implikacje biznesowe

Status: [N] Normatywny Odbiorca: Zarząd | Compliance | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 10.1, 10.7, 14.1, 16.10

Struktura korporacyjna SYLION jest trójstopniowa i celowo zaprojektowana z myślą o optymalnej jurysdykcji, segmentacji rynkowej i ochronie prywatności klientów:

Swiss AG (Aktiengesellschaft) — główny podmiot prawny: - Kontrakty komercyjne i prywatne globalnie - Wszystkie europejskie kontrakty komercyjne - Jurysdykcja sprzyjająca prywatności, brak ekspozycji na CLOUD Act - Kontrakty z klientami prywatnymi (osoby fizyczne, dziennikarze, politycy, NGO) — wyłącznie ze Szwajcarii lub USA - Właściciel IP (intellectual property) i licencji

US LLC/Corp — podmiot dla rynku amerykańskiego: - Wejście na rynek USA, kontrakty z klientami US - Ścieżka FedRAMP (wymaga US legal entity) - Kontrakty STATE z klientami, których wymogi zamówień wymagają podmiotu US - Lokalne partnerstwa z US-based MSSP i integratorami

Polish Sp. z o.o. — podmiot operacyjny: - Zespół development - Operacje bieżące - Spółka zależna UE - Koszt operacyjny (niższe stawki dev w PL vs CH/US)

Kontrakty STATE/SOVEREIGN: sprzedawane ze Szwajcarii lub USA, w zależności od jurysdykcji klienta i wymogów jego procedur zamówień publicznych. Np. kontrakt z europejskim ministerstwem — realizowany przez Swiss AG. Kontrakt z kontrahentorem DoD USA — realizowany przez US LLC/Corp.

Implikacja dla klientów prywatnych: Dziennikarze, politycy, NGO — obsługiwani wyłącznie ze Szwajcarii lub USA. Swiss AG zapewnia, że dane klienta podlegają szwajcarskiemu prawu o ochronie prywatności (nDSG/revDSG), jednemu z najsilniejszych na świecie. Klient prywatny nie jest narażony na jurysdykcyjne mechanizmy przymusowego dostępu.

10.13 Monetyzacja modułów premium i pakiety usług

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Niski Powiązane rozdziały: 10.7, 14.4, 14.5

Moduł Matrix homeserver (opcjonalny add-on). Dedykowany homeserver Matrix per-operator lub per-tenant, zapewniający pełną kontrolę nad metadanymi komunikacyjnymi. Koszt: +20 €/operator/miesiąc dodawane do ceny subskrypcji. Wpływa na marżę: koszt infrastruktury per-operator rośnie z ~66 € do ~86

€/miesiąc, lecz przychód rośnie o 20 € — marża netto na module jest neutralna (moduł jest dostarczany at-cost jako element wartości dodanej, nie jako profit center).

Moduł PQC (Post-Quantum Cryptography). Hybridowe szyfrowanie post-kwantowe dla wszystkich kanałów komunikacyjnych. Status: [R] dla tieru STATE od 2028, [O] dla pozostałych tierów. Cena: dodatek do subskrypcji per-operator.

Moduł Confidential Computing. AMD SEV-SNP lub Intel TDX encryption-in-use. Status: [R] dla tieru STATE od 2028. Wyższy koszt infrastruktury (dedykowany hardware z TEE), przeniesiony na klienta jako premium.

Moduł dark-Matrix (sovereign comms). Pełna kontrola nad federacją Matrix: brak zewnętrznej federacji, dedykowany homeserver z izolacją hardware.

Pakiety professional services: POC 30 dni, wdrożenie produkcyjne, roczny red team, roczny compliance review, dedykowany threat intelligence feed.

Rozdział 11. Segmentacja rynku i persony

11.1 Segmenty klientów docelowych — Faza 1 (Europa)

Status: [N] Normatywny Odbiorca: Zarząd | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 9.7, 10.1, 11.2–11.6, 16.1

Faza 1 GTM (startująca teraz) koncentruje się na pięciu segmentach europejskich, wybranych według czterech kryteriów: (a) natychmiastowość potrzeby, (b) wysoka gotowość do zapłacenia premium (Willingness to Pay — WTP), (c) brak złożonego cyklu zamówień publicznych, (d) zdolność do generowania referencji dla późniejszej sprzedaży enterprise/government.

#	Segment	Tier docelowy	Cena	Typowa wielkość	WTP	Cykl sprzedaży
1	Kancelarie prawne	STANDARD / PRO	400–1 500 €/op/mies.	10–200 operatorów	Bardzo wysoka	30–90 dni
2	Dziennikarze śledczy	PRO	1 500 €/op/mies.	1–50 operatorów	Wysoka (+ granty)	7–30 dni
3	Politycy opozycji	PRO	1 500 €/op/mies.	1–20 operatorów	Wysoka	7–30 dni
4	NGO / organizacje praw człowieka	PRO	1 500 €/op/mies.	5–100 operatorów	Średnia–Wysoka	30–60 dni
5	Kadra zarządzająca high-risk	PRO	1 500 €/op/mies.	5–30 operatorów	Bardzo wysoka	30–90 dni

Logika sekwencji — dlaczego te segmenty pierwsze:

Tradycyjna strategia SaaS B2B zaczyna od „enterprise regulated” i buduje w górę do government. SYLION celowo odwraca tę sekwencję — zaczyna od segmentów o najwyższym profilu zagrożeń (dziennikarze, politycy, prawnicy), a nie od największych budżetów. Powody:

Najtrudniejsze case studies budują najsilniejsze referencje. Jeśli SYLION chroni dziennikarza śledczego przed Pegasusem, argument dla CISO korporacji jest trywialny. Jeśli SYLION chroni kancelarię obsługującą transakcję M&A o wartości miliarda euro — argument dla ministerstwa jest oczywisty.

Brak bariery certyfikacyjnej. Kancelarie prawne, dziennikarze i politycy nie wymagają ISO 27001, FIPS 140-3 ani Common Criteria. Mogą kupić subskrypcję natychmiast. Segmenty rządowe i obronno-przemysłowe wymagają certyfikacji, które zajmą 1–3 lata.

Krótki cykl sprzedaży. Dziennikarz kupuje subskrypcję PRO w ciągu dni. Kancelaria prawna decyduje w ciągu tygodni. Ministerstwo — w ciągu 12–24 miesięcy. Cash flow w pierwszych miesiącach wymaga szybkich konwersji.

Budowanie narrative. „SYLION chroni tych, którzy chronią prawdę” jest silniejszym przekazem marketingowym niż „SYLION jest kolejnym narzędziem compliance dla enterprise”. Narrative przyciąga uwagę mediów, konferencji i potencjalnych inwestorów.

11.2 Kancelarie prawne (Priorytet 1)

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 10.2, 11.1, 14.1

Kancelarie prawne są idealnym klientem pierwszego dnia z kilku powodów strukturalnych:

Obowiązek prawny ochrony danych. Tajemnica adwokacka (legal privilege / Berufsgeheimnis / tajemnica radcowska) jest prawnie chroniona w każdej jurysdykcji. Kancelaria, która nie chroni komunikacji z klientem na adekwatnym poziomie, narusza regulacje zawodowe i naraża się na sankcje dyscyplinarne, roszczenia cywilne i utratę reputacji. SYLION dostarcza architektoniczny dowód adekwatnej ochrony — zero danych na terminalu, audit trail, CDR, izolacja per-operator.

Ryzyko ataków celowanych. Kancelarie obsługujące transakcje M&A, spory korporacyjne, sprawy antytrustowe, arbitraże międzynarodowe są celem szpiegostwa gospodarczego. Przeciwnicy procesowi, fundusze aktywistyczne, agencje wywiadowcze — wszyscy mają motywację do uzyskania dostępu do komunikacji prawnika. Kancelarie obsługujące klientów z jurysdykcji wrażliwych (Rosja, Chiny, Bliski Wschód) są narażone na zagrożenia state-level.

Wysoka gotowość do zapłacenia. Stawki godzinowe partnerów w top kancelariach to 500–1 500 €/h. Roczny koszt SYLION STANDARD (400 €/miesiąc) to ekwiwalent mniej niż jednej godziny pracy partnera. SYLION PRO (1 500 €/miesiąc) to 1–3 godziny pracy. Koszt jest mikroskopijny w kontekście przychodów kancelarii — nie wymaga złożonego procesu budżetowego.

Przypadki użycia: - Data room M&A: 10 prawników × PRO = 15 000 €/miesiąc. Izolowane env-office, CDR, audit trail. Po zakończeniu transakcji workspace kryptograficznie zniszczony. - Komunikacja z klientem regulowanym: Kancelaria obsługująca bank podlegający DORA musi wykazać, że komunikacja jest chroniona adekwatnie. SYLION generuje artefakty compliance automatycznie. - Ochrona przed discovery w litygacji US: Dokumenty na SYLION są chronione przez zero-knowledge architecture — w przypadku discovery request, terminal nie zawiera żadnych danych.

Tier docelowy: STANDARD (400 €/op/mies.) dla większości prawników w kancelarii, PRO (1 500 €/op/mies.) dla partnerów zarządzających i zespołów M&A. Typowe wdrożenie: 80% STANDARD, 20% PRO.

11.3 Dziennikarze śledczy (Priorytet 2)

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 10.3, 11.1, 13.13

Profil operatora: Dziennikarze Bellingcat, OCCRP, Forbidden Stories, niezależne redakcje w państwach autorytarnych, dziennikarze freelance pracujący nad wrażliwymi tematami (korupcja, przestępczość zorganizowana, inwigilacja państwowa).

Scenariusze zagrożeń: (1) ataki Pegasus/Predator — zero-click exploitation telefonu; (2) fizyczna konfiskata urządzenia — na granicy, przy zatrzymaniu; (3) wymuszony dostęp (coercive interrogation); (4) inwigilacja sieciowa — monitoring ruchu na poziomie ISP/state.

Dlaczego SYLION: Istniejące rozwiązania (Signal, SecureDrop, Tor) chronią komunikację, lecz nie eliminują danych z endpointu. Dziennikarz z zainstalowanym Signalem na telefonie — po konfiskacie urządzenia adversarz uzyskuje dostęp do listy kontaktów, historii komunikacji (jeśli nie wyczyszczona), metadanych sesji. SYLION eliminuje ten wektor architektonicznie: terminal nie zawiera danych, kluczy ani historii.

Tier docelowy: PRO (1 500 €/op/mies.). Sprzedaż ze Szwajcarii (Swiss AG). Finansowanie: budżet redakcji, granty od organizacji wspierających wolność prasy (Freedom of Press Foundation, Reporters Without Borders, CPI), dedykowane programy bezpieczeństwa cyfrowego (EU Horizon, USAID digital security grants).

Zbieżność z misją Freedom of Press Foundation: SYLION adresuje dokładnie te same zagrożenia, które FPF dokumentuje — inwigilacja dziennikarzy przez państwa. Partnerstwo z FPF i RSF jest naturalnym elementem strategii GTM dla tego segmentu.

Wartość strategiczna: Endorsement przez znanego dziennikarza śledczego (np. scenariusz: „Reporter X ujawnił korupcję na najwyższych szczeblach — jego komunikacja była chroniona przez SYLION”) generuje rozpoznawalność marki wartą miliony w ekwiwalencie reklamowym. Segment ten jest „billboardem bezpieczeństwa” SYLION.

11.4 Politycy opozycji i osoby publiczne (Priorytet 3)

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 10.3, 11.1, 13.13

Profil klienta: Politycy opozycji w państwach z aktywnym ryzykiem inwigilacji, europosłowie, posłowie parlamentów krajowych, lokalni politycy zaangażowani w wrażliwe tematy (whistleblowing, antykorupcja), członkowie rodzin polityków.

Dlaczego osobny segment (nie „government”): Politycy opozycji są klientami prywatnymi — nie korzystają z infrastruktury rządowej (której nie kontrolują i której nie ufają). Nie podlegają procedurom zamówień publicznych. Mogą kupić subskrypcję PRO jako osoby fizyczne. Jednocześnie ich profil zagrożeń jest porównywalny z profilem government (inwigilacja przez obce wywiady, targeting przez służby krajowe, ataki APT).

Scenariusze zagrożeń: (1) inwigilacja przez krajowe służby specjalne (historia: Pegasus użyty przeciwko politykom opozycji w Polsce, Hiszpanii, Węgrzech, Grecji, Tajlandii); (2) targeting przez obce wywiady (komunikacja polityka o strategicznym znaczeniu); (3) konfiskata urządzenia przy dochodzeniu prokuratorskim.

Tier docelowy: PRO (1 500 €/op/mies.). Sprzedaż wyłącznie ze Szwajcarii lub USA (Swiss AG / US LLC). Brak złożoności zamówień rządowych — polityk kupuje jako osoba prywatna lub przez fundację/partię.

Pakiet hardware: Google Pixel najnowszej generacji (900 €) + router podróżny (150 €) + YubiKey Bio (200 €) = 1 250 € jednorazowo. Polityk otrzymuje gotowy do pracy zestaw — onboarding w <5 minut.

11.5 NGO i organizacje praw człowieka (Priorytet 4)

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 10.3, 11.1, 13.11, 13.13

Profil organizacji: Human Rights Watch, Amnesty International, MSF, ICRC, lokalne organizacje praw człowieka operujące w strefach konfliktu i państwach autorytarnych, organizacje monitorujące wybory, organizacje antykorupcyjne.

Specyficzne wymagania: (a) tryb terenowy — łączność satelitarna (Starlink), ograniczona przepustowość; (b) wieloosobowe zespoły rozproszone geograficznie; (c) ochrona danych beneficjentów (osoby chronione, świadkowie, ofiary); (d) budżet ograniczony — organizacje non-profit.

Model cenowy: PRO (1 500 €/op/mies.) z potencjalnym pricing dostosowanym dla organizacji non-profit. Finansowanie: granty cyberbezpieczeństwa (EU Horizon, USAID, Open Technology Fund, Ford Foundation). SYLION może oferować dedykowane pakiety „NGO Security Package” ze specjalną ceną, finansowaną z wyższych marż segmentu enterprise.

11.6 Kadra zarządzająca wysokiego ryzyka (Priorytet 5)

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 10.2, 10.5, 11.1, 13.12

Profil: CEO, CFO, członkowie zarządów i rad nadzorczych firm prowadzących wrażliwe operacje (M&A, restrukturyzacja, IPO), dyrektorzy narażeni na aktywizm inwestorski (activist investors), board members z dostępem do materiałów niejawnych, executive assistants z dostępem do komunikacji zarządu.

Dlaczego osobny segment: Executive protection jest rosnącym rynkiem — firmy inwestują w fizyczną ochronę zarządu (bodyguards, secure transport), lecz ignorują cyfrową ochronę komunikacji. Wyciek strategii cenowej, planu przejścia czy wyników finansowych przed publikacją może kosztować setki milionów w utraconej wartości akcji lub przegranym procesie.

Tier docelowy: PRO (1 500 €/op/mies.). Typowe wdrożenie: 5–30 operatorów (zarząd + selected advisors). Roczny koszt: $5 \times 1\,500 \text{ €} \times 12 = 90\,000 \text{ €}$ (5-osobowy zarząd) — koszt trivialny w kontekście budżetów executive protection.

Kryteria zakupowe: User experience (CEO nie będzie korzystał z narzędzia, które jest skomplikowane), dyskrecja (terminal nie powinien wyglądać inaczej niż standardowy telefon), szybkość wdrożenia (zarząd nie ma czasu na tygodniowe szkolenia).

11.7 Segmenty Fazy 2 — Defence-adjacent i Government

Status: [R] Rekomendowany Odbiorca: Zarząd | Compliance | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 10.4, 11.1, 14.9, 16.10

Faza 2 uruchamiana po uzyskaniu pierwszych certyfikacji (ISO 27001, ścieżka FIPS 140-3):

Defence-adjacent: Kontrahenci wojskowi (Defence Industrial Base), konsultanci obronni, biura bezpieczeństwa parlamentarnego. Wymagają certyfikacji, lecz mają mniej złożone procedury zamówień niż ministerstwa. Tier: STATE (minimum 50 operatorów = minimum 125 000 €/miesiąc = 1,5 mln €/rok).

Government: Narodowe agencje cyberbezpieczeństwa, ministerstwa spraw zagranicznych, podmioty intelligence-adjacent (nie bezpośrednio wywiad — początkowo). Wymaga: Common Criteria evaluation path, security clearance personelu, referencje z defence-adjacent. Tier: STATE z pełnym wdrożeniem sovereign.

Cykl sprzedaży: 12–24 miesięcy. Etapy: RFI → RFP → POC/pilot → audyt bezpieczeństwa → decyzja zakupowa (poziom ministerialny).

Strategia cold start: Pierwsza referencja rządowa jest najtrudniejsza. Strategia: (a) wdrożenie pilotowe w podmiocie government-adjacent; (b) uzyskanie certyfikacji krajowej; (c) konwersja pilotu w produkcję; (d) wykorzystanie referencji w przetargach.

11.8 Segmenty Fazy 3 — Rynek USA

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Średni Powiązane rozdziały: 9.7, 16.1

Wejście na rynek USA przez istniejące europejskie referencje: - Kancelarie prawne US — największy rynek prawny na świecie, wysoka gotowość do zapłacenia premium, kultura ochrony legal privilege - Dziennikarze US — First Amendment protection culture, silna tradycja ochrony źródeł, organizacje jak Freedom of Press Foundation - FedRAMP jako cel długoterminowy (2–3 lata po wejściu europejskim) - Partner US-based MSSP dla dystrybucji — SYLION nie buduje własnej siły sprzedaży w US w Fazie 3, lecz współpracuje z partnerem posiadającym relacje i kompetencje FedRAMP

Sprzedaż przez US LLC/Corp. Model: channel sales przez partnera US + direct sales dla klientów strategic.

11.9 Persona: Managing Partner kancelarii prawnej

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Średni Powiązane rozdziały: 11.2, 16.1

Rola w procesie zakupowym: Decision maker. Managing Partner decyduje o narzędziach bezpieczeństwa kancelarii. Jego priorytet: ochrona tajemnicy adwokackiej, reputacja kancelarii, compliance.

Motywacje: (1) ochrona reputacji — incydent bezpieczeństwa w kancelarii to koniec zaufania klientów; (2) obowiązek regulacyjny — izby adwokackie zastrzegają wymagania cyberbezpieczeństwa; (3) przewaga konkurencyjna — „nasza kancelaria używa architektury zero-knowledge” jest selling point wobec klientów wrażliwych.

Co Managing Partner chce usłyszeć: „Jeśli FBI/ABW/DGSI skonfiskuje telefon Twojego partnera, nie znajdą na nim ani jednej wiadomości od klienta. Zero. Architektonicznie niemożliwe. Roczny koszt: mniej niż godzina pracy partnera miesięcznie.”

Obiekcje typowe: (1) „czy to wygodne?” — odpowiedź: latencja <100ms, porównywalna z VDI; (2) „czy muszę zmieniać telefon?” — odpowiedź: Pixel z GrapheneOS w pakiecie startowym za 1 250 €; (3) „co jeśli nie będzie internetu?” — odpowiedź: router podróży w pakiecie, Starlink jako opcja; (4) „ile to kosztuje?” — odpowiedź: 400 € miesięcznie per prawnik (tier STANDARD), 1 500 € dla partnerów zarządzających (tier PRO).

11.10 Persona: Dziennikarz śledczy

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 11.3, 13.13

Profil: Pracuje nad wrażliwymi tematami. Podróżuje do krajów z aktywną inwigilacją. Chroni źródła za wszelką cenę. Niski poziom wiedzy technicznej, wysoki poziom stresu operacyjnego.

Co dziennikarz mówi o SYLION: „Nie obchodzi mnie jak to działa. Obchodzi mnie: czy moje źródła są bezpieczne? Czy jak zabiorą mi telefon na granicy, to nic nie znajdą? Czy mogę wysłać materiał do redakcji, gdy mam tylko Starlink? Czy baterię wytrzyma do wieczora?”

Wymagania UX: Onboarding w <5 minut. Zero konfiguracji technicznej. Panic button — szybkie zerowanie terminala. Jasny wskaźnik statusu łączności.

11.11 Persona: CISO enterprise

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Niski Powiązane rozdziały: 11.1, 11.6, 16.1

Rola w procesie zakupowym: Decision maker lub key influencer w segmencie enterprise i government-adjacent (Fazy 2–3).

Co CISO chce usłyszeć: „Eliminujemy dane na endpointach — to największa redukcja attack surface, jaką możesz osiągnąć jedną decyzją. Mamy immutable audit trail, mapowanie do NIS2/DORA/ISO 27001 out-of-the-box i 5-year TCO z kalkulacją marży. Koszt infrastruktury per-operator: 66 €, cena subskrypcji: 400 €/STANDARD, 1 500 €/PRO — transparentna struktura kosztów. Oto ROI calculator.”

11.12 Persona: Administrator IT i Partner Integrator

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Niski Powiązane rozdziały: 10.6, 11.1, 16.5

Administrator IT zarządza wdrożeniem SYLION w organizacji klienta. Priorytet: łatwość zarządzania, automatyzacja, dokumentacja, wsparcie.

Partner Integrator wdraża SYLION u klientów. Priorytet: wiedza, narzędzia, marża, wsparcie.

Co partner chce usłyszeć: „Dajemy ci szkolenie, certification exam, first deployment support, leady z naszego pipeline, 20–30% marży na kontrakcie. Kontrakt STATE to minimum 1,5 mln €/rok per klient — twoja marża na jednym wdrożeniu pokrywa roczny koszt certyfikacji partnera. ROI z partnerstwa: pozytywny po pierwszym wdrożeniu STATE.”

Rozdział 12. Analiza konkurencji i pozycjonowanie

12.1 Kategorie konkurentów: bezpośredni

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Partner Wpływ na baseline: Średni Powiązane rozdziały: 12.2, 12.5, 12.6, 12.13

Macierz luk Hypori vs SYLION (research kwiecień 2026):

Funkcja	Hypori	SYLION
---------	--------	--------

CDR file sanitization	Brak	OPSWAT Deep CDR (100% SE Labs)
Suwerenna komunikacja	Właściwy, zamknięty, niefederacyjny	Matrix — otwarty, federacyjny, NATO/Bundeswehra
Post-quantum VPN	Brak	IPsec IKEv2 + ML-KEM-1024 (CNSA 2.0)
Split Gateway G1/G2	Brak (single TLS proxy)	Tak — rozdzielenie sieci od logiki dostępu
Utwardzony endpoint	Brak (consumer devices)	GrapheneOS + duress PIN + USB-C block + MTE
Mikrosegmentacja per-operator	Per-user ARM instance	Dedykowany VPS per operator + microVM per workload
Hosting EU	Brak (AWS GovCloud US only)	Szwajcaria, EU sovereign cloud
Tryb offline	Brak (wymaga 500Kbps–5Mbps)	Briar mesh fallback
API	Brak	REST/gRPC/GraphQL
Windows workspace	Brak	Desktop jako równorzędny terminal
Jurysdykcja	USA (CLOUD Act, FISA)	Szwajcaria (poza Five Eyes, nDSG)

Hypori: \$82.3M funding, ~35 pracowników, FedRAMP High (marzec 2025), IL5 PA do 2028. Cena: ~\$20–40/user/mc enterprise.

Konkurenci bezpośredni SYLION 3.0 to platformy oparte na modelu VMI (Virtual Mobile Infrastructure) lub VDI (Virtual Desktop Infrastructure), które pozycjonują się jako rozwiązania bezpiecznej komunikacji lub pracy zdalnej z eliminacją danych na endpointcie.

Hypori (USA, FedRAMP High, DoD IL5 High) — jedyny komercyjny konkurent bezpośredni o porównywalnym modelu architektonicznym. Szczegółowa analiza w podrozdziale 12.5.

Citrix Virtual Apps and Desktops — tradycyjne VDI/DaaS. Architektonicznie podobne (zdalne wykonanie), lecz fundamentalnie odmienne w modelu bezpieczeństwa: współdzielona infrastruktura, brak mikrosegmentacji per-user, brak Zero Trust natywnego, brak CDR.

VMware Horizon (Broadcom/VMware) — VDI enterprise. Podobne ograniczenia jak Citrix.

Amazon WorkSpaces — DaaS od AWS. Brak Split Gateway, brak CDR, brak komunikacji szyfrowanej (Matrix/Signal), brak immutable infrastructure.

Żaden z wymienionych nie łączy czterech elementów definiujących SYLION: Zero Trust + remote app model + Split Gateway + per-operator micro-segmentation.

12.2 Kategorie konkurentów: pośredni (ZTNA, MDM, VPN)

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Partner Wpływ na baseline: Średni Powiązane rozdziały: 12.1, 12.7, 12.13

ZTNA: Zscaler, Cloudflare Access, Palo Alto Prisma Access. Zabezpieczają dostęp, nie eliminują danych na endpointcie.

MDM: Microsoft Intune, Jamf Pro, SOTI MobiControl. Zarządzają urządzeniami, dane wciąż rezydują na endpointcie. Remote wipe wymaga łączności.

VPN: Cisco AnyConnect, Palo Alto GlobalProtect, NordLayer. Szyfrują transport, nie chronią danych w spoczynku na endpointcie.

Secure Messaging: Signal, Threema Work, Wickr, Element (Matrix). Dane na endpointcie (historia, klucze, kontakty), brak pełnego środowiska pracy.

12.3 Kategorie konkurentów: alternatywy (self-hosted Matrix, Signal, Threema)

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Partner Wpływ na baseline: Niski Powiązane rozdziały: 12.1, 12.6, 12.13

Self-hosted Matrix (Synapse/Dendrite + Element). Open-source, suwerenne wdrożenie, dobra szyfrawa. Ograniczenia: dane na endpointcie, brak Thin Client, brak Split Gateway, brak CDR, brak mikrosegmentacji, brak ścieżki certyfikacyjnej out-of-the-box. SYLION buduje na Matrix, nie konkuruje z Matrix.

Signal. Nie wspiera self-hosting enterprise. Dane na endpointcie. SYLION wykorzystuje Signal jako degradowany workload kompatybilnościowy wewnątrz VPS operatora.

Threema Work. Szwajcarski komunikator enterprise. Dane na endpointcie, brak Thin Client, nie jest platformą pracy.

12.4 Kategorie konkurentów: rozwiązania specjalistyczne

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Partner Wpływ na baseline: Niski Powiązane rozdziały: 12.1, 12.7, 12.13

PRA (Privileged Remote Access): BeyondTrust, CyberArk. Fokus na sesje administratorskie, nie na pełne środowisko pracy.

RBI (Remote Browser Isolation): Menlo Security, Zscaler Cloud Browser Isolation. Izolacja przeglądarki — architektonicznie najbliższe SYLION, lecz ograniczone do przeglądarki. RBI jest jednym workloadem w SYLION (env-browser).

DLP (Data Loss Prevention): Symantec, Forcepoint, Microsoft Purview. Operują na endpointcie — implant na urządzeniu może obejść DLP. SYLION eliminuje potrzebę DLP na endpointcie.

12.5 Hypori — szczegółowa analiza konkurencyjna

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 12.1, 12.6, 12.8, 12.13

Hypori (Reston, Virginia, USA) jest najbliższym komercyjnym odpowiednikiem SYLION. Analiza Hypori jako benchmark jest kluczowa dla pozycjonowania. Hypori waliduje rynek — potwierdza, że model VMI/pixel-streaming jest akceptowany przez najbardziej wymagających klientów (DoD, agencje federalne).

16.5.1 12.5.1 Co Hypori ma, a SYLION jeszcze nie

Uczciwa analiza wymaga przyznania przewag Hypori:

Przewaga Hypori	Stan	Implikacja dla SYLION
-----------------	------	-----------------------

FedRAMP High Authorization (marzec 2025)	Uzyskane	SYLION na ścieżce — cel 2029+
DISA IL5 High Provisional Authorization (do 2028)	Uzyskane	SYLION nie planuje IL5 w horyzoncie 3 lat
NIAP Common Criteria (NSA CSfC listed)	Uzyskane	SYLION — CC EAL4+ Rok 3
US government reference customers	Ustalone	SYLION buduje referencje od Fazy 1 (Europa)
Większy ekosystem integratorów US	Ustalone	SYLION buduje ekosystem EU + US partner

Hypori posiada przewagę certyfikacyjną 2–3 lata i ustalone relacje z US government. Są to realne, istotne przewagi.

16.5.2 12.5.2 Co SYLION ma, a Hypori nie — 9 przewag architektonicznych

#	Wymiar	Hypori	SYLION	Implikacja
1	Jurysdykcja	US-only, ITAR-adjacent, brak EU sovereign deployment	Europejska firma, Swiss AG, sovereign on-premise possible	Klienci EU nie mogą/nie chcą używać US platform (CLOUD Act)
2	Zakres funkcjonalny	Fokus na mobile messaging	Pełna platforma pracy: Matrix + Office + CRM + Browser + Analytics + Voice	SYLION zastępuje cały stos pracy, nie tylko komunikator
3	Architektura gateway	Single trust boundary (brak split gateway)	Split Gateway G1/G2, defence-in-depth	SYLION: kompromitacja G1 nie daje dostępu do workloadu
4	Izolacja operatorów	Shared infrastructure (per-device, nie per-operator)	Per-operator micro-segmentation w dedykowanych 3 VPS	SYLION: kompromitacja jednego operatora ≠ kompromitacja innych
5	CDR pipeline	Basic file transfer (nie CDR)	Pełny CDR staging z sanityzacją	SYLION: każdy plik rozbierany, oczyszczany, rekonstruowany
6	Komunikacja rdzeniowa	Zależna od komercyjnej infrastruktury messagingowej	Własny homeserver Matrix, zero zewnętrznych metadanych	SYLION: pełna suwerenność komunikacyjna
7	Confidential Computing	Brak udokumentowanej ścieżki SEV-SNP/TDX	Ścieżka Confidential Computing w tierze STATE	SYLION: ochrona danych in-use w horyzoncie 2028
8	Pricing	Nieprzejrzysty, US DoD focused	Transparentne europejskie ceny: 400/1 500/2 500+ €	SYLION: klient wie, ile zapłaci, zanim zadzwoni
9	Hardware starter kit	Brak — operator musi sam zapewnić endpointy	Turnkey hardware package: Pixel + router + FIDO2 = 1 250 €	SYLION: gotowy do pracy zestaw z jednego źródła

16.5.3 12.5.3 Pozycjonowanie vs Hypori — synteza

SYLION nie konkuruje z Hypori front-to-front na rynku US DoD — Hypori ma tam ugruntowaną pozycję, FedRAMP High i referencje. SYLION pozycjonuje się jako: Europejska alternatywa dla klientów, którzy nie chcą/nie mogą powierzyć danych infrastrukturze podlegającej CLOUD Act

Szersza platforma (full work platform vs mobile messaging only)

Głębsza architektura bezpieczeństwa (G1/G2 split, per-operator microVM, CDR, Matrix sovereign, Confidential Computing path)

Transparentne ceny (400/1 500/2 500+ € vs nieprzejrzysty cennik DoD)

12.6 Matrix/Element jako punkt odniesienia

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Partner Wpływ na baseline: Średni Powiązane rozdziały: 12.1, 12.3, 12.5, 12.13

Element (firma stojąca za protokołem Matrix) jest drugim kluczowym punktem odniesienia. SYLION nie konkuruje z Matrix — buduje na Matrix. Matrix jest rdzeniem komunikacyjnym SYLION.

Czego Matrix/Element nie robią (i co SYLION dodaje):

Brak w Matrix/Element	SYLION adresuje
Model Thin Client	Terminal = zero-knowledge pixel renderer
Dane na endpointzie	Zero danych na terminalu
Split Gateway	Architektura G1/G2
CDR pipeline	Pipeline CDR per-operator
Mikrosegmentacja per-operator	3 dedykowane VPS per-operator
Immutable infrastructure	IaC, zniszcz i odbuduj
Pełne środowisko pracy	Office, CRM, browser, analytics
Ścieżka FIPS/CNSA 2.0	IPsec IKEv2 (nie WireGuard)

12.7 ZTNA, VDI, RBI jako punkty odniesienia

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Partner Wpływ na baseline: Niski Powiązane rozdziały: 12.1, 12.2, 12.4, 12.13

ZTNA: Komplementarne do SYLION (SYLION może korzystać z ZTNA jako warstwy dostępowej). ZTNA adresuje „kto i jak łączy się z zasobem”; SYLION adresuje „gdzie rezydują dane”.

VDI: Architektonicznie najbliższe — zdalne pulpity. Kluczowe różnice: współdzielone farmy (vs izolacja per-operator), zaufany klient wymagany (vs zero-knowledge terminal), brak CDR/Zero Trust/mikrosegmentacji, masywna powierzchnia ataku (Citrix CVE historia).

RBI: Architektonicznie bliskie (pixel rendering), lecz ograniczone do przeglądarki. RBI jest jednym workloadem w SYLION (env-browser).

12.8 Tabela porównawcza wartości

Poniższa tabela porównuje propozycje wartości SYLION z kluczowymi konkurentami według czterech wymiarów: głębokości bezpieczeństwa, suwerenności danych, certyfikowalności i modelu cenowego.

SYLION osiąga unikalną pozycję w kwadrancie wysokiej suwerenności i wysokiej głębokości bezpieczeństwa — jednocześnie oferując certyfikowalny rdzeń, europejskie jurisdiction i transparentny cennik. Hypori przewodzi w certyfikacjach DoD, ale jest ograniczony do jurysdykcji US i infrastruktury AWS GovCloud. Citrix i standardowe VDI oferują zdalne pulpity, lecz bez mikrosegmentacji per-operator i bez eliminacji danych na endpointach.

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 12.1–12.7, 12.13

Cecha	SYLION 3.0	Hypori	Element/Matrix	VDI (Citrix)	ZTNA (Zscaler)	MDM (Intune)
Zero data on endpoint	✓	✓	✗	⚠ ✗ ✗ (partial)		
Per-operator microVM isolation	✓ (3 VPS)	⚠ ✗ ✗ ✗ (per-device)	✗			
Split Gateway G1/G2	✓	✗	✗	✗	✗	✗
CDR pipeline	✓	✗	✗	✗	✗	✗
Matrix-based comms	✓	✗	✓	✗	✗	✗
Full work platform	✓	⚠ (messaging c (✗ only)	omms only) ✓ ✗ ✗			
Sovereign deployment	✓	⚠ (US only) ✗ ✓ ✓	✗			
Immutable infrastructure	✓	?	✗	✗	✗	✗
Confidential Computing path	✓	✗	✗	✗	✗	✗
European origin	✓ (Swiss AG)	✗ (US)	✓ (UK)	✗ (US)	✗ (US)	✗ (US)
Hardware starter kit	✓ (1 250 €)	✗	✗	✗	✗	✗
Transparent pricing	✓ (400/1 500/2 500+)	✗	✓ (open source)	⚠ ⚠ ✓		

16.9 12.9–12.11 Tabele porównawcze: architektura, bezpieczeństwo, certyfikacje

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Infra | SOC | Compliance Wpływ na baseline: Niski Powiązane rozdziały: 12.8, 12.13

Architektura:

Element	SYLION 3.0	Hypori	VDI (Citrix/VMware)
Model wykonania	Per-operator 3× microVM (Firecracker)	VMI (per-user VM)	Współdzielona farma
Izolacja compute	3 dedykowane VPS (G1+G2+workload)	VM per-user	Shared hypervisor
Transport	IPsec IKEv2 (FIPS/CNSA path)	TLS	ICA/Blast (proprietary)
Komunikacja	Matrix (open, sovereign homeserver)	Proprietary	Brak natywnej
CDR	Natywny pipeline z sanitizacją	Basic file transfer	Brak
TEE support	SEV-SNP/TDX (planned, tier STATE)	Brak	Brak

Certyfikacje:

Certyfikacja	SYLION 3.0	Hypori	Element
FedRAMP High	Ścieżka 2029+	✓ (marzec 2025)	✗
Common Criteria	Ścieżka EAL4+ Rok 3	✓ (NIAP)	✗
FIPS 140-3	Ścieżka Rok 2	?	✗
ISO 27001	Ścieżka Rok 1	?	✓
GDPR compliance	Natywne (Swiss AG, EU origin)	⚠ (US, CLOUD U (✓ Act risk)	K)

12.12 Matryca pozycjonowania

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Niski Powiązane rozdziały: 12.8–12.11, 12.13

Matryca na dwóch osiach: suwerenność × głębokość bezpieczeństwa.

Kwadrant I (wysoka suwerenność + wysoka głębokość): SYLION 3.0 (tier STATE/SOVEREIGN). Jedyna platforma łącząca pełne suwerenne wdrożenie z głęboką architekturą bezpieczeństwa.

Kwadrant II (niska suwerenność + wysoka głębokość): Hypori. Wysoka głębokość (FedRAMP High, IL5), ograniczona suwerenność (AWS GovCloud only, US jurisdiction, CLOUD Act).

Kwadrant III (wysoka suwerenność + średnia głębokość): Self-hosted Matrix/Element, on-premise VDI. Pełna kontrola nad infrastrukturą, lecz dane na endpointach.

Kwadrant IV (niska suwerenność + niska głębokość): ZTNA SaaS, MDM SaaS, cloud messaging.

SYLION celowo pozycjonuje się w Kwadrancie I — jedynym kwadrancie bez ustalonej konkurencji.

12.13 Unfair advantages

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 8.1, 9.1, 12.1–12.12

SYLION 3.0 posiada sześć przewag strukturalnych (unfair advantages):

1. Jedyna platforma łącząca cztery elementy. Zero Trust + remote app model + Split Gateway G1/G2 + per-operator mikrosegmentacja (3 dedykowane VPS). Hypori posiada dwa z czterech, Citrix jeden.
2. Certyfikowalny rdzeń projektowany od dnia 1. Certyfikowalność nie jest retrofitowana. Harmonogram: ISO 27001 Rok 1, FIPS 140-3 Rok 2, CC EAL4+ Rok 3.
3. Suwerenność Matrix. Własny homeserver Matrix — zero zewnętrznych metadanych. Hypori: zależność od komercyjnej infrastruktury messagingowej. Signal: centralny relay US.
4. Europejskie pochodzenie i struktura Swiss AG. Natywna zgodność z GDPR, brak CLOUD Act. Dla klientów europejskich eliminuje fundamentalne ryzyko jurysdykcyjne.
5. Infrastruktura immutable jako zasada rdzeniowa. Każdy komponent odtwarzalny z IaC. Eliminuje klasy ataków (persistent backdoors, configuration drift).
6. Turnkey hardware package. Pixel + router + FIDO2 = 1 250 € jednorazowo, gotowy do pracy. Hypori nie oferuje — operator musi sam zapewnić endpointy. Dla segmentów Fazy 1 (dziennikarze, politycy) — kompletność rozwiązania jest kluczowa.

Rozdział 13. Scenariusze użycia

13.1 Bezpieczna komunikacja tekst/głos/wideo (Matrix)

Status: [N] Normatywny Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.6, 13.2, 13.7, 12.6

Podstawowy scenariusz użycia SYLION 3.0 — bezpieczna komunikacja oparta na protokole Matrix jako rdzeniu komunikacyjnym.

Podróż operatora (operator journey): (1) Operator otwiera terminal (Pixel/GrapheneOS lub laptop). (2) Uruchamia aplikację SYLION — nawiązanie sesji pikselowej z VPS operatora przez tunel IPsec IKEv2 via bramki G1/G2. (3) Na ekranie terminala wyświetla się środowisko pracy — w tym klient Matrix (Element lub dedykowany frontend). (4) Operator pisze wiadomość — tekst jest wpisywany na terminalu, przesyłany jako input do VPS, przetwarzany w kliencie Matrix na VPS, szyfrowany end-to-end (Megolm/MLS) i wysyłany do homeservera Matrix. (5) Odbiorca (inny operator SYLION lub użytkownik sfederowanego homeservera) otrzymuje wiadomość przez swój klient Matrix.

Kluczowe właściwości bezpieczeństwa: (a) wiadomość jest szyfrowana E2E — nawet homeserver Matrix nie widzi treści; (b) klucze sesyjne rezydują w VPS operatora, nie na terminalu; (c) historia komunikacji jest przechowywana w zaszyfrowanym storage VPS, nie na terminalu; (d) metadane (kto z kim, kiedy) są ograniczone do homeservera SYLION — brak wycieków do zewnętrznych serwerów; (e) połączenia głosowe i wideo wykorzystują SRTP z opcjonalnym SFrame (Blind Broker — status [R] dla audio/video, [E] dla remote desktop channel).

Voice i video: Matrix natywnie wspiera voice i video calls (VoIP, WebRTC). W SYLION audio i video są renderowane w VPS operatora — terminal odbiera strumień pikselowy zawierający obraz kamery i strumień audio. Latencja voice: cel < 150ms (akceptowalne dla konwersacji). Latencja video: cel < 200ms. Optymalizacja: bezpośredni tunel voice/video między VPS operatorów w tym samym tenantcie (unikanie podwójnego pixel-encoding).

13.2 Praca z dokumentami (env-office)

Status: [N] Normatywny Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.6, 13.1, 13.3, 13.7

Drugie kluczowe środowisko pracy — edycja dokumentów biurowych w izolowanym środowisku chmurowym.

Podróż operatora: (1) Operator przełącza się do środowiska office w swoim workspace SYLION. (2) Na ekranie (renderowanym pikselowo z VPS) widzi pakiet biurowy kompatybilny z formatami Microsoft Office (DOCX, XLSX, PPTX). (3) Operator tworzy lub edytuje dokument — cała praca odbywa się w VPS; na terminalu nie jest zapisywany ani tymczasowy plik, ani cache dokumentu. (4) Zapis dokumentu — dokument jest zapisywany w zaszyfrowanym storage VPS operatora. (5) Udostępnienie innemu operatorowi — transfer przez CDR staging: plik jest poddawany sanitacji (Content Disarm & Reconstruct), a następnie udostępniany w workspace docelowego operatora.

Izolacja env-office: Środowisko biurowe działa w oddzielnym workloadzie (lub oddzielnej mikroVM) od środowiska komunikacyjnego. Izolacja zapobiega: (a) exfiltracji danych z dokumentów przez kanał komunikacyjny (lub odwrotnie) bez przejścia przez CDR; (b) exploitom w pakiecie biurowym wpływającym na komunikację; (c) malware w dokumentach (otrzymanych z zewnątrz) rozprzestrzeniającym się na inne workloady.

CDR przy transferze dokumentów: Każdy dokument transferowany między operatorami lub importowany z zewnątrz przechodzi pipeline CDR: rozbicie na elementy składowe (tekst, obrazy, metadata), usunięcie aktywnych komponentów (makra, skrypty, embedded objects), rekonstrukcja czystego dokumentu. CDR jest natywnym mechanizmem SYLION — nie wymaga zewnętrznego produktu (choć integracja z zewnętrznymi silnikami CDR jest wspierana).

13.3 CRM i analityka (env-crm)

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 8.6, 13.2, 13.4

Środowisko CRM (Customer Relationship Management) i analityki operacyjnej — izolowane środowisko pracy z kontrolowanym dostępem do zewnętrznych API.

Podróż operatora: (1) Operator przełącza się do środowiska CRM. (2) Widzi interfejs CRM (np. SuiteCRM, Odoo lub dedykowany frontend) renderowany pikselowo z VPS. (3) Operator wprowadza dane klienta, notatki ze spotkań, statusy szans sprzedażowych. (4) CRM komunikuje się z zewnętrznymi systemami (ERP klienta, system fakturowy) przez kontrolowany API bridge — ruch wychodzący przechodzi przez egress proxy z whitelistingiem domen i inspekcją treści. (5) Dane CRM rezydują w zaszyfrowanym storage VPS — nigdy na terminalu.

Kontrola dostępu API: Środowisko CRM wymaga dostępu do zewnętrznych API — co stanowi potencjalny kanał eksfiltracji danych. Kontrola: (a) whitelist domen/IP — środowisko CRM może łączyć się wyłącznie z autoryzowanymi endpointami; (b) inspekcja payloadów — egress proxy analizuje treść zapytań API pod kątem

eksfiltracji (DLP na poziomie proxy); (c) rate limiting — ograniczenie wolumenu transferu; (d) audit logging — każde zapytanie API jest logowane z pełnym kontekstem.

13.4 Dostęp do internetu (env-browser)

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 8.6, 13.1, 13.3, 12.7

Środowisko przeglądarkowe — izolowane środowisko do bezpiecznego przeglądania internetu, architektonicznie zbliżone do modelu RBI (Remote Browser Isolation).

Podróż operatora: (1) Operator przełącza się do środowiska browser. (2) Na ekranie widzi przeglądarkę (Chromium lub Firefox) działającą w VPS — strony internetowe są renderowane w chmurze, terminal odbiera jedynie piksele. (3) Operator przegląda internet — cały ruch HTTP/HTTPS wychodzi z VPS przez egress proxy. (4) Pobrany plik (PDF, DOCX, obraz) jest zapisywany w storage VPS i poddawany CDR przed udostępnieniem w innych środowiskach.

Izolacja env-browser: Przeglądarka jest najczęściej exploitowanym komponentem — dlatego środowisko browser jest izolowane od środowisk komunikacyjnych i biurowych. Exploit w przeglądarce (0-day w V8/SpiderMonkey, malicious website) jest zamknięty w mikroVM przeglądarki i nie może dotknąć komunikacji Matrix ani dokumentów biurowych. Po zakończeniu sesji przeglądarkowej mikroVM może być zniszczona i odbudowana (ephemeral browsing).

Egress control: Cały ruch z env-browser przechodzi przez egress proxy: (a) whitelist/blacklist domen; (b) TLS inspection (opcjonalnie, z pełną transparentnością dla operatora); (c) logging; (d) filtrowanie treści (malware, phishing). Egress proxy jest skonfigurowany per-tenant — każdy klient definiuje polityki przeglądania dla swoich operatorów.

13.5 Integracja z systemami zewnętrznymi

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner Wpływ na baseline: Średni Powiązane rozdziały: 8.6, 10.6, 13.3, 13.4

SYLION 3.0 nie operuje w próżni — musi integrować się z istniejącą infrastrukturą klienta (SIEM, IAM, ITSM, ERP, email) w sposób kontrolowany i audytowalny.

Wzorce integracji: (a) API bridge outbound — workloady SYLION komunikują się z systemami klienta przez kontrolowany API bridge z whitelistingiem, inspekcją i logowaniem; (b) API bridge inbound — systemy klienta odpytują management plane SYLION (provisioning, polityki, logi) przez uwierzytelnione REST API; (c) SIEM integration — logi bezpieczeństwa i audytowe są eksportowane do SIEM klienta (Syslog, CEF, STIX/TAXII); (d) IAM integration — uwierzytelnienie operatorów przez SAML 2.0 / OIDC z IdP klienta (Azure AD, Okta, Keycloak); (e) ITSM integration — zdarzenia SYLION generują tickety w systemie ITSM klienta (ServiceNow, Jira Service Management) przez webhooks.

Zasada bezpieczeństwa integracji: Każda integracja jest punktem potencjalnego wycieku danych. Zasady: (a) minimum privilege — integracja uzyskuje dostęp wyłącznie do danych niezbędnych do funkcjonowania; (b) audit — każda operacja integracyjna jest logowana; (c) encryption in transit — TLS 1.3 minimum; (d) API keys w HSM — credentials integracyjne zarządzane przez HSM, nie przechowywane w plaintext; (e) rate limiting i anomaly detection — monitoring wzorców użycia API pod kątem eksfiltracji.

13.6 Współpraca zespołowa (Team Collaboration)

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 13.1, 13.2, 13.7

Scenariusz współpracy zespołowej łączy komunikację Matrix z udostępnianiem dokumentów i wspólną pracą w izolowanych środowiskach.

Podróż zespołu: (1) Zespół (np. 5 operatorów w dziale prawnym) posiada wspólny Matrix room. (2) Operatorzy komunikują się tekstowo i głosowo w room'ie. (3) Jeden operator tworzy dokument w env-office, zapisuje go w shared workspace zespołu. (4) Dokument przechodzi CDR staging (nawet przy transferach wewnątrz tenanta — defence-in-depth). (5) Inni operatorzy otwierają dokument w swoich env-office — każdy widzi ten sam plik, lecz pracuje w swoim izolowanym VPS. (6) Zmiany są synchronizowane przez kontrolowany mechanizm (nie przez direct file sharing — przez CDR-guarded sync).

Separacja między tenantami: Współpraca jest możliwa wewnątrz tenanta (operatorzy tego samego klienta). Współpraca między tenantami (operatorzy różnych klientów) wymaga: (a) jawnej federacji Matrix między homeserverami; (b) CDR na granicy tenantów; (c) zatwierdzenia przez administratorów obu tenantów. Zasada: mikrosegmentacja jest domyślnie zamknięta — otwarcie kanału wymaga jawnej decyzji.

13.7 Współpraca zespołowa — zaawansowana

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 13.1, 13.6, 8.6

Matrix rooms stanowią naturalny framework współpracy: rooms mogą być publiczne (wewnątrz tenanta), prywatne (zaproszenie), szyfrowane E2E (domyślnie dla SYLION). Rooms wspierają: tekst, voice, video, pliki (via CDR staging), integracje (boty, bridges).

Konferencje voice/video: Matrix natywnie wspiera konferencje (Element Call, Jitsi bridge). W SYLION konferencje odbywają się wewnątrz infrastruktury tenanta — media server działa w VPS, strumienie nie opuszczają infrastruktury klienta (dla wdrożeń suwerennych). Konferencje cross-tenant wymagają jawnej federacji i przechodzą przez bramki G2.

Kontrolowany cross-operator file transfer: Transfer pliku między operatorami: (1) operator A „eksportuje” plik do CDR staging; (2) CDR sanityzuje plik (rozbiecie, usunięcie aktywnych komponentów, rekonstrukcja); (3) plik pojawia się w inbox CDR operatora B; (4) operator B „importuje” plik do swojego env-office. Proces jest jawny i audytowalny — w przeciwieństwie do tradycyjnych platform, gdzie pliki przepływają swobodnie.

13.8 Tryb kryzysowy i awaryjny

Status: [N] Normatywny Odbiorca: Architekt | Infra | SOC | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 9.6, 13.13, 11.6

Scenariusz kryzysowy opisuje zachowanie systemu w warunkach degradacji — utrata łączności, atak na infrastrukturę, konieczność natychmiastowej ewakuacji.

Utrata łączności internetowej: SYLION w modelu bazowym wymaga łączności z VPS — bez internetu sesja pikselowa nie jest możliwa. Degradacja: (a) operator traci dostęp do wszystkich środowisk pracy; (b) dane pozostają bezpieczne w VPS (nie ulegają zniszczeniu); (c) po odzyskaniu łączności operator odzyskuje pełny dostęp.

Moduł offline fallback ([E]) umożliwia ograniczone funkcjonowanie: cache wybranych danych w zaszyfrowanej enklawie na terminalu z TTL (Time to Live) i automatyczną destrukcją.

Dead man switch. Mechanizm automatycznej reakcji na brak aktywności operatora: jeśli operator nie potwierdzi statusu w zdefiniowanym oknie czasowym (np. 24h), system: (a) powiadamia administratora; (b) opcjonalnie blokuje sesje operatora; (c) opcjonalnie inicjuje kryptograficzną destrukcję wybranych workloadów. Konfiguracja per-operator, zatwierdzana przez administratora.

Emergency revoke. Administrator (lub operator z odpowiednimi uprawnieniami) może natychmiastowo odwołać dostęp operatora: (a) zakończenie wszystkich aktywnych sesji; (b) revoke certyfikatów i tokenów; (c) zablokowanie nowych logowań; (d) opcjonalnie: kryptograficzna destrukcja workloadów operatora. Czas od decyzji do pełnego revoke: < 30 sekund.

Backup authentication paths. Jeśli podstawowe uwierzytelnienie (MFA + certyfikat) jest niedostępne (utrata tokena MFA, uszkodzenie certyfikatu): (a) recovery code (wygenerowany przy onboarding, przechowywany offline); (b) administrator-assisted recovery (admin generuje tymczasowy token, operator musi zmienić credentials w ciągu godziny); (c) hardware token backup (zapasowy FIDO2 key).

13.9 Tryb mobilny

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 8.5, 11.10, 13.10, 13.11

Terminal mobilny — Google Pixel z GrapheneOS — jest podstawowym urządzeniem dostępowym SYLION 3.0 dla operatorów mobilnych.

Hardware referencyjny: Google Pixel (najnowszy dostępny model) z GrapheneOS. Wybór Pixel wynika z: (a) najlepsze wsparcie GrapheneOS (jedyne hardware z pełnym wsparciem verified boot i hardware-backed attestation); (b) regularne patche bezpieczeństwa; (c) chip Titan M2 (secure element); (d) dostępność globalna; (e) brak bloatware. Ograniczenie: zależność od jednego producenta hardware (zidentyfikowane ryzyko, patrz 9.9).

Wymagania sieciowe: minimalna przepustowość dla sesji pikselowej: 2 Mbps (niska jakość, tekst czytelny), rekomendowana: 5 Mbps (płynna praca), optymalna: 10+ Mbps (video, multimedia). Latencja: < 100ms rekomendowana, < 150ms akceptowalna, > 200ms degradacja doświadczenia. Sieci wspierane: WiFi, LTE/4G, 5G. VPN over cellular: IPsec IKEv2 jest stabilny na sieciach mobilnych dzięki MOBIKE (RFC 4555) — obsługa zmiany IP bez renegotiacji sesji.

Zarządzanie baterią: Sesja pikselowa + stały tunel IPsec to obciążenie energetyczne. Optymalizacje: (a) adaptive quality — redukcja jakości strumienia pikselowego przy niskim poziomie baterii; (b) sleep mode — zamrożenie sesji po zdefiniowanym czasie nieaktywności (tunel IPsec utrzymany, strumień pikselowy wstrzymany); (c) background optimization — minimalizacja wakelock'ów i background processing.

13.10 Tryb desktopowy

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 8.5, 13.9, 13.11

Terminal desktopowy — zarządzany laptop (Linux) — jest podstawowym urządzeniem dostępowym dla operatorów stacjonarnych i semi-mobilnych.

Hardware referencyjny: Laptop enterprise (Lenovo ThinkPad, Dell Latitude) z zarządzanym Linux (Fedora Silverblue / NixOS — immutable OS). Klient SYLION na desktopie: natywna aplikacja pikselowa lub przeglądarka (WebRTC-based pixel streaming). Desktop zapewnia: (a) większy ekran — lepsza ergonomia pracy z dokumentami; (b) pełna klawiatura — szybsza praca tekstowa; (c) stabilniejsza łączność (Ethernet); (d) możliwość wielomonitorowej pracy (dwa środowiska SYLION obok siebie).

Zarządzanie terminalem desktopowym: Immutable OS (Silverblue, NixOS) zapewnia: (a) brak możliwości trwałej modyfikacji systemu (rootkit-resistant); (b) aktualizacje atomowe (rollback w razie problemów); (c) zarządzanie konfiguracją deklaratywne (Nix, ostree). MDM dla laptopów: SYLION management agent monitoruje stan systemu (OS version, patch level, encryption status) i raportuje compliance.

13.11 Tryb terenowy (Field Deployment)

Status: [R] Rekomendowany Odbiorca: Architekt | Infra | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 11.5, 11.6, 13.9, 13.13

Wdrożenie terenowe obejmuje scenariusze, w których operatorzy pracują w warunkach ograniczonej łączności, niestabilnej infrastruktury i podwyższonego ryzyka fizycznego.

Scenariusze terenowe: dziennikarz w strefie konfliktu, dyplomata na placówce w kraju niestabilnym, pracownik NGO w regionie bez stałej infrastruktury, inżynier na budowie w terenie oddalonym.

Wymagania specyficzne: (a) łączność satelitarna (Starlink, Iridium) — sesja pikselowa musi być użyteczna na łączach o przepustowości 2–5 Mbps i latencji 40–600ms (Starlink: ~40ms, Iridium: ~600ms); (b) power management — praca na baterii przez 8+ godzin; (c) fizyczne bezpieczeństwo terminala — wstrząsoodporność, wodoodporność (Google Pixel: IP68); (d) szybkie zerowanie — procedura wipe w < 10 sekund; (e) backup connectivity — SIM failover, WiFi mesh, Bluetooth tethering.

Hardware dodatkowy dla scenariuszy terenowych: (a) powerbank (minimum 20000 mAh); (b) terminal Starlink Mini (jeśli brak infrastruktury naziemnej); (c) faradayowa torba (blokowanie sygnałów radiowych — ochrona przed triangulacją gdy terminal nie jest w użyciu); (d) zapasowy terminal SYLION (w przypadku utraty/zniszczenia głównego).

13.12 Rozszerzone scenariusze branżowe

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Niski Powiązane rozdziały: 10.2, 10.3, 10.4, 11.2–11.6

Finanse — M&A data room: Zespół M&A (5–10 operatorów) pracuje nad przejęciem. Wszystkie dokumenty (due diligence, term sheet, wyceny) rezydują w izolowanym env-office na SYLION. Komunikacja z doradcami przez Matrix rooms z E2E encryption. Dostęp ściśle kontrolowany — każdy operator widzi tylko autoryzowane dokumenty. Audit trail rejestruje każde otwarcie dokumentu. Po zakończeniu transakcji workspace może być kryptograficznie zniszczony. Wartość: wyciek planu przejęcia może kosztować setki milionów — SYLION eliminuje ten wektor.

Prawo — poufna komunikacja z klientem: Kancelaria prawna obsługująca klienta w sprawie antytrustowej. Komunikacja objęta tajemnicą adwokacką (legal privilege). SYLION izoluje workspace per-sprawa, CDR kontroluje przepływ dokumentów, audit trail dokumentuje każdy dostęp. W przypadku discovery request —

klient może udowodnić, że dane były chronione adekwatnie.

Ochrona zdrowia — dane pacjentów: Szpital lub sieć klinik operująca z danymi pacjentów (GDPR art. 9 — dane szczególne). SYLION izoluje workspace lekarzy, dane pacjentów nie opuszczają VPS, dostęp kontrolowany per-lekarz per-pacjent. Compliance z GDPR, HIPAA (jeśli operacje w USA), krajowymi regulacjami ochrony zdrowia.

Obronność — zespoły terenowe: Kontrahent obronny (DIB) prowadzący operacje w terenie. Komunikacja z centralą przez SYLION, dokumenty techniczne w env-office, raporty w env-crm. Terminale mobilne (Pixel) odporne na fizyczne przejęcie — zero danych. Tier: PRO lub STATE w zależności od klasyfikacji danych.

Dziennikarstwo — ochrona źródeł: Dziennikarz śledczy komunikuje się ze źródłem przez Matrix na SYLION. Źródło nie jest identyfikowalne nawet w przypadku fizycznego przejęcia terminala dziennikarza. Dokumenty od źródła przechodzą CDR. Komunikacja nie jest przechowywana na terminalu. W przypadku wezwania sądownego — terminal nie zawiera żadnych danych.

Dyplomacja — wymiana klasyfikowana: Ambasada komunikuje się z MSZ przez SYLION tier STATE. Suwerenne wdrożenie na lokalnych serwerach, brak zależności od zagranicznej chmury. Szyfrowanie end-to-end z kluczami zarządzanymi przez krajowy HSM. Terminale w ambasadach nie przechowują żadnych danych — nawet w przypadku fizycznego przejęcia placówki, dane komunikacyjne pozostają bezpieczne w suwerennym centrum danych.

13.13 Scenariusze specjalne i wysokiego ryzyka

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | SOC | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 8.4, 11.5, 11.6, 13.8, 13.11

Scenariusze opisane w niniejszym podrozdziale adresują ekstremalnie wymagające warunki operacyjne, w których adversarz dysponuje zasobami na poziomie państwowym lub quasi-państwowym. SYLION jest architektonicznie zaprojektowany tak, aby w każdym z tych scenariuszy zminimalizować ekspozycję danych i tożsamości operatora.

Przekroczenie wrogiej granicy (hostile border crossing): Operator podróżuje z terminalem SYLION przez punkt kontroli granicznej państwa uznanego za wroga. Służby graniczne mogą: (a) zażądać odblokowania urządzenia — terminal nie zawiera danych, galerii, historii przeglądania, dokumentów; (b) sklonować pamięć urządzenia — klon zawiera jedynie system operacyjny GrapheneOS i aplikację klienta pikselowego, bez artefaktów pracy; (c) zatrzymać urządzenie — operator zgłasza utratę, platforma revokuje certyfikat terminala, provisioning nowego terminala w ciągu 15 minut z dowolnego zapasowego Pixela. Kluczowa zasada: terminal jest wymienny, dane są niezniszczalne (bo rezydują w VPS).

Konfiskata urządzenia (device seizure): Organy ścigania konfiskują terminal na podstawie nakazu. Procedura kryptograficznego zniszczenia (cryptographic destroy): (a) operator inicjuje remote wipe — jeśli zdążył; (b) platforma automatycznie revokuje certyfikat terminala po 24h braku kontaktu (configurable dead man switch); (c) terminal po factory reset nie zawiera żadnych śladów pracy — brak artefaktów forensic. Nawet analiza NAND flash (chip-off) nie ujawni danych roboczych, bo nigdy nie istniały na urządzeniu.

Przesłuchanie pod przymusem (coercive interrogation): Operator pod presją fizyczną lub psychologiczną jest zmuszany do ujawnienia dostępu. Mechanizmy ochronne: (a) duress PIN — alternatywny PIN, który uruchamia fałszywy profil z neutralnymi danymi lub inicjuje wipe; (b) canary mechanism — brak zalogowania w zdefiniowanym oknie czasowym uruchamia procedury ochronne (revokacja certyfikatu, powiadomienie SOC); (c) separacja wiedzy — operator nie posiada kluczy szyfrujących dane (klucze zarządzane przez HSM, operator autentkuje się, ale nie posiada zdolności deszyfrowania offline). Ograniczenie: duress PIN wymaga wcześniejszej konfiguracji i przeszkolenia operatora; jest elementem [O] Opcjonalnym, nie baseline.

Przejęcie infrastruktury (infrastructure takedown): Adversarz państwowy przejmuje kontrolę nad centrum danych lub providerem chmurowym. Procedura odbudowy: (a) cała infrastruktura SYLION jest definiowana jako IaC (Infrastructure as Code); (b) rebuild kompletnego środowiska produkcyjnego w nowej lokalizacji w czasie < 30 minut (zautomatyzowane); (c) dane operatorów zaszyfrowane kluczami z HSM — nawet przejęcie dysków nie ujawnia treści; (d) procedura migracji DNS/IP — operatorzy łączą się z nowym endpoint w ciągu 1h od przełączenia. Warunek: wymaga wdrożenia multi-region backup i procedur DR opisanych w Części V.

Nadzór na poziomie państwowym (state-level surveillance): Adversarz prowadzi pasywny i aktywny nadzór na poziomie ISP/telco. Mechanizmy ochronne: (a) cały ruch terminalOW–G1 jest tunelowany przez IPsec IKEv2 — nie ma ruchu cleartext; (b) egress proxy zapobiega korelacji metadanych (ruch z VPS wychodzi przez shared egress, utrudniając fingerprinting); (c) IMSI rotation (legalna, model Cape MVNO) — utrudnia triangulację; (d) minimalizacja metadanych — brak metadanych leaks na poziomie protokołu; (e) traffic padding [E] — eksperymentalne generowanie sztucznego ruchu maskującego wzorce aktywności. Ograniczenie: analiza ruchu (traffic analysis) na poziomie global passive adversary pozostaje otwartym problemem badawczym — SYLION minimalizuje, lecz nie eliminuje tego wektora.

Rozdział 14. Modele licencjonowania, ceny i subskrypcje

14.1 Modele ofertowe — przegląd

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 10.7, 10.8, 14.2–14.12

Benchmark cenowy konkurencji (research kwiecień 2026):

Rozwiązanie	Cena/user/mc	Zakres
Citrix DaaS	€25–54	VDI (bez komunikacji)
OmniSSA Horizon	od €5	VDI (bez komunikacji)
Zscaler ZPA	€6–25	ZTNA (bez workspace)
Element Enterprise	€3–4/MAU	Komunikacja (bez workspace)
Threema Work	€3–5	Komunikacja CH (bez workspace)
Wire Enterprise	€7.50–9	Komunikacja MLS (bez workspace)
AWS Wickr	€5–15	Komunikacja FedRAMP
BlackBerry SecuSUITE	€15–50+	Komunikacja rządowa (CC, NATO)

Hypori	~€20–40	VMI + messaging (FedRAMP High)
Typowy enterprise stack (złożony)	€83–171	M365 + VDI + ZTNA + PAM + messaging
Gov/defense stack (złożony)	€178–551	Sovereign infra + SecuSUITE + SOC
SYLION STANDARD	€400	Pełna platforma
SYLION PRO	€1 500	+ Confidential Computing + Heartbeat
SYLION STATE	od €2 500	+ Sovereign + HSM + PQC + wdrożenie

SYLION pozycjonuje się w segmencie 3–17× powyżej typowych kosztów enterprise — uzasadnione dedykowaną infrastrukturą per-operator, suwerenną jurysdykcją szwajcarską i certyfikowalnym rdzeniem.

SYLION oferuje jeden podstawowy model rozliczeniowy — subskrypcję per-operator per-miesiąc — z trzema tierami cenowymi. Model ten zapewnia prostą kalkulację kosztów, bezpośrednie powiązanie wydatków z liczbą użytkowników i przewidywalność zarówno dla klienta, jak i dla SYLION.

Model per-operator (primary): Klient płaci stałą miesięczną opłatę za każdego aktywnego operatora. Opłata obejmuje: izolowane środowisko VPS operatora (3 instancje: G1 + G2 + workload), dostęp do wszystkich modułów wchodzących w skład wybranego tieru, wsparcie techniczne na odpowiednim poziomie, aktualizacje platformy, monitoring bezpieczeństwa.

Pakiet hardware’owy (jednorazowy, sprzedawany oddzielnie): Zestaw terminalowy per-operator, niezależny od subskrypcji. Klient kupuje hardware jednorazowo, subskrypcja jest oddzielnym zobowiązaniem. Szczegóły w 14.5.

Model per-tenant (MSP): Dla partnerów MSSP oferujących SYLION swoim klientom końcowym. Partner płaci za tenant, wewnętrznie rozlicza się z klientami.

14.2 Tiers — porównanie funkcjonalności i cen

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 3.4, 10.7, 14.1, 14.3

SYLION definiuje trzy tiery produktowe. Każdy wyższy tier zawiera wszystkie funkcjonalności tieru niższego plus rozszerzenia:

18.2.1 Cennik

Tier	Cena	Subskrypcja	Min. operatorów	Zawiera
STANDARD	400 €/operator/miesiąc	6 miesięcy lub 12 miesięcy	Brak minimum	Pełna platforma
PRO	1 500 €/operator/miesiąc	Wyłącznie 12 miesięcy	Brak minimum	Platforma + rozszerzony SOC + szybszy SLA
STATE/SOVEREIGN	od 2 500 €/operator/miesiąc	Indywidualnie (min. 12 mies.)	Minimum 50 operatorów	Platforma + professional deployment + custom implementation

18.2.2 Tabela funkcjonalności

Funkcjonalność	STANDARD	PRO	STATE/SOVEREIGN
Izolowane 3× VPS per-operator (G1+G2+workload)	✓	✓	✓
Sesja pikselowa (remote desktop)	✓	✓	✓
Matrix E2E comms	✓	✓	✓
IPsec IKEv2 transport	✓	✓	✓
CDR file transfer	✓	✓	✓
Split Gateway G1/G2	✓	✓	✓
Per-operator micro-segmentation	✓	✓	✓
Firecracker microVM isolation	✓	✓	✓
Immutable infrastructure	✓	✓	✓
Rozszerzony monitoring SOC	—	✓	✓
Szybszy SLA wsparcia	—	✓	✓
Wiele compute dla mikroVM	—	✓	✓
HSM key management	—	✓	✓
Confidential Computing (SEV-SNP/TDX) ścieżka	—	—	✓
PQC hybrydowe szyfrowanie ścieżka	—	—	✓
Sovereign deployment (on-prem)	—	—	✓
Air-gap mode ścieżka	—	—	✓
Dedykowany HSM on-premise	—	—	✓
Professional deployment service	—	—	✓ (wliczone)
Feature adaptation (custom implementation)	—	—	✓ (wliczone)
Dedicated SOC monitoring	—	—	✓
SLA 99.95%	—	—	✓

18.2.3 Analiza ekonomiczna per tier

STANDARD (400 €/operator/miesiąc): - Koszt infrastruktury bazowy: ~66 €/operator/miesiąc (bez Matrix) / ~86 € (z Matrix) - Marża brutto przed kosztami ludzkimi: ~79–84% - Subskrypcje: 6 lub 12 miesięcy - Brak minimalnej liczby operatorów — umożliwia sprzedaż pojedynczym osobom i małym kancelariom - Typowy klient Fazy 1: kancelaria prawna (10–200 operatorów)

PRO (1 500 €/operator/miesiąc): - Koszt infrastruktury: ~86 €/operator/miesiąc (Matrix wliczony, więcej compute) - Marża brutto przed kosztami ludzkimi: ~94% - Subskrypcja wyłącznie 12 miesięcy — wymusza commitment, stabilizuje przychody - Brak minimalnej liczby operatorów — umożliwia sprzedaż pojedynczym dziennikarzom i politykom - Typowy klient Fazy 1: dziennikarz śledczy, polityk opozycji, zarząd korporacji

STATE/SOVEREIGN (od 2 500 €/operator/miesiąc): - Koszt infrastruktury: ~100–120 €/operator/miesiąc (dedykowany hardware, CC path) - Komponent professional services wliczony w cenę - Marża brutto (na infrastrukturze): ~80–88% - Marża po alokacji services: ~70–80% - Minimum 50 operatorów = minimum 125 000 €/miesiąc = 1 500 000 €/rok per klient - Obejmuje profesjonalne usługi wdrożeniowe i adaptację funkcjonalną (custom implementation) - Typowy klient Fazy 2: kontraktor obronny, ministerstwo, agencja narodowa

14.3 Zasady cenowe

Status: [N] Normatywny Odbiorca: Zarząd | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 10.7, 10.8, 14.1, 14.2

Zasada transparentności cenowej: Ceny są jawne i opublikowane. Klient zna koszt przed pierwszym kontaktem z zespołem sprzedaży. Transparentność jest przewagą konkurencyjną — Hypori nie publikuje cennika. SYLION publikuje: 400 € / 1 500 € / od 2 500 €.

Zasada premium positioning: SYLION konkuruje jakością i bezpieczeństwem architektonicznym, nie ceną. 400 € za STANDARD to premium wobec tradycyjnych narzędzi (MDM + VPN + messaging łącznie ~50 €/operator/miesiąc), ale uzasadnione eliminacją danych z endpointu, izolacją per-operator, CDR, Split Gateway i immutable infrastructure.

Zasada brak minimum dla STANDARD i PRO: Pojedynczy dziennikarz, polityk lub prawnik może kupić subskrypcję bez minimalnego commitmentu ilościowego. Decyzja ta jest celowa — umożliwia natychmiastowe pozyskanie klientów Fazy 1 bez bariery „minimum 10/25/50 operatorów”.

Zasada minimum 50 operatorów dla STATE: Kontrakty STATE wymagają dedykowanego wdrożenia, custom implementation i professional services. Minimum 50 operatorów (= minimum 125 000 €/miesiąc) zapewnia, że kontrakt jest ekonomicznie uzasadniony po stronie SYLION — koszty professional services i dedykowanego wsparcia rozkładają się na wystarczającą bazę operatorów.

14.4 Rozszerzenia i moduły dodatkowe

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 10.12, 14.2

Matrix homeserver (opcjonalny add-on): +20 €/operator/miesiąc dodawane do ceny subskrypcji. Dedykowany homeserver Matrix per-operator lub per-tenant, pełna kontrola nad metadanymi komunikacyjnymi. Koszt infrastruktury: +20 €/operator/miesiąc — moduł dostarczany at-cost jako element wartości dodanej. Łączny koszt infrastruktury z Matrix: ~86 €/operator/miesiąc.

PQC Module (Post-Quantum Cryptography): Hybrydowe szyfrowanie post-kwantowe. Domyślnie włączone w tierze STATE od 2028, dostępne jako płatne rozszerzenie dla STANDARD i PRO.

Confidential Computing Tier: AMD SEV-SNP lub Intel TDX. Domyślnie w tierze STATE, opcjonalne rozszerzenie. Wymaga hardware capability w centrum danych.

Dark-Matrix Sovereign Comms: Dedykowany, izolowany homeserver Matrix bez federacji. Absolutna izolacja komunikacyjna.

Micro-watermarking Module: Niewidoczne znakowanie wodne dokumentów i ekranów. [O] Opcjonalny — aktywowany per-tenant.

14.5 Pakiet hardware’owy (jednorazowy)

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 8.5, 10.7, 14.2

Pakiet hardware’owy jest sprzedawany oddzielnie od subskrypcji. Jest to jednorazowy koszt per-operator, niezależny od wybranego tieru subskrypcji.

Komponent	Specyfikacja	Cena
Router podróży	GL-iNet Beryl AX (MT-3000) lub równoważny z obsługą OpenWrt + IPsec IKEv2	150 €
Terminal mobilny	Google Pixel (najnowszy dostępny model) z GrapheneOS	900 €
Klucz FIDO2	Biometryczny klucz hardware (np. Yubico YubiKey Bio)	200 €
Łączny pakiet startowy		1 250 € per operator (jednorazowo)

Starlink: Operator może pozyskać niezależnie. Nie jest częścią pakietu SYLION — cena i dostępność Starlink różni się między rynkami. SYLION zapewnia kompatybilność (sesja pikselowa jest użyteczna na łączach Starlink o przepustowości 2–5 Mbps i latencji ~46ms USA (mediana Ookla) / ~80ms EU (IFIP 2025)).

Uzasadnienie pakietu: - Router podróży zapewnia bezpieczny transport IPsec IKEv2 niezależnie od sieci WiFi hotelow/kawiarnianych. Operator łączy się z routerem, router tuneluje ruch do G1 gateway. - Google Pixel z GrapheneOS to jedyny hardware z pełnym wsparciem verified boot, hardware-backed attestation (Titan M2) i regularnymi patchami bezpieczeństwa. GrapheneOS eliminuje telemetrię Google. - YubiKey Bio zapewnia MFA odporne na phishing (FIDO2/WebAuthn) z weryfikacją biometryczną (odcisk palca na kluczu, nie na telefonie).

Cel sprzedaży hardware Rok 1: 100 zestawów startowych = 125 000 € przychodu jednorazowego. Marża na hardware: ~20–30% (SYLION kupuje komponenty w cenach nieco poniżej retail).

14.6 Modele rozliczeniowe

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 14.1, 14.3

Subskrypcja 6-miesięczna (STANDARD only): Opłata naliczana z góry za 6 miesięcy. Gwarantowana minimalna liczba operatorów na okres subskrypcji. Możliwość zwiększenia liczby operatorów w trakcie okresu. Brak automatycznego odnowienia — wymaga jawnej decyzji.

Subskrypcja 12-miesięczna (STANDARD i PRO): Opłata roczna naliczana z góry lub w ratach kwartalnych. Dla STANDARD: opcjonalnie lekka zniżka wobec 6-miesięcznej. Dla PRO: jedyna dostępna opcja (12 miesięcy wymusza commitment).

Kontrakt STATE (minimum 12 miesięcy, indywidualnie): Umowa negocjowana indywidualnie. Minimum 50 operatorów. Rozliczenie miesięczne, kwartalne lub roczne — negocjowalne. Typowo 2–3 lata (procedury zakupowe sektora publicznego wymagają długoterminowych zobowiązań). Gwarancja cenowa na okres kontraktu.

Rozliczenie hardware: Jednorazowe, przy dostawie. Fakturowane przez Swiss AG lub US LLC w zależności od jurysdykcji klienta.

14.7 Pakiety usług profesjonalnych

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Niski Powiązane rozdziały: 10.13, 16.2–16.4

POC Package (30 dni): Pełnofunkcyjny proof of concept dla maksymalnie 10 operatorów. Provisioning, konfiguracja terminali, onboarding, szkolenie, raport. Koszt: ryczałtowy, zaliczany na poczet kontraktu produkcyjnego.

Deployment Package (STANDARD/PRO): Wdrożenie produkcyjne: architektura, provisioning, konfiguracja, onboarding, integracja (SSO, SIEM), szkolenie, testy akceptacyjne. 4–12 tygodni.

Deployment Package (STATE): Kompletnie wdrożenie sovereign z professional services wliczonymi w cenę subskrypcji. Obejmuje: adaptację funkcjonalną (custom implementation), instalację on-premise, konfigurację HSM, szkolenie personelu (SRE + SOC), testy bezpieczeństwa rozszerzone. 12–24 tygodni.

Annual Red Team Package: Roczny program testów bezpieczeństwa — 1 pełny pentest + 2 testy scenariuszowe + quarterly tabletop exercise.

Compliance Review Package: Gap analysis, przygotowanie dokumentacji dowodowej, wsparcie podczas audytu.

14.8 Tiers wsparcia technicznego

STANDARD: Wsparcie przez portal (ticketing), SLA odpowiedzi: P1 — 4h, P2 — 8h, P3 — 24h. Dostęp do bazy wiedzy i dokumentacji. Godziny pracy: CET business hours.

PRO: Wsparcie przez portal + email, dedykowany Customer Success Manager (CSM) przypisany do tenanta. SLA odpowiedzi: P1 — 2h, P2 — 4h, P3 — 12h. Kwartalne przeglądy techniczne. Proaktywne powiadomienia o zmianach wpływających na konfigurację operatora.

STATE/SOVEREIGN: Dedykowany Technical Account Manager (TAM) z clearance. Wsparcie 24/7 dla incydentów P1. SLA: P1 — 1h, P2 — 2h. Możliwość wdrożenia on-premises zespołu wsparcia. Minimum: roczny kontrakt z 125 000 EUR minimum.

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 14.2, 15.7, 16.2

Parametr	Standard Support	Priority Support	Dedicated Support
Dostępność	8/5 (dni robocze)	12/7	24/7/365
First response (P1)	< 4h	< 1h	< 15 min
First response (P2)	< 8h	< 2h	< 1h
First response (P3)	< 24h	< 8h	< 4h
Dedykowany opiekun	—	—	✓
Eskalacja do inżyniera	via ticket	via telefon	direct Matrix
Quarterly review	—	✓	✓
Included in tier	STANDARD	PRO	STATE/SOVEREIGN

14.9 Licencjonowanie sovereign (on-premise)

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 10.4, 11.7, 14.2, 16.10

Wdrożenia sovereign (tier STATE/SOVEREIGN, od 2 500 €/operator/miesiąc, minimum 50 operatorów) obejmują pełne usługi wdrożeniowe i adaptację funkcjonalną w cenie subskrypcji.

Zakres STATE: Subskrypcja obejmuje: oprogramowanie platformy SYLION (control plane, data plane, management plane), IaC templates, dokumentację operacyjną, runbooki, professional deployment service, feature adaptation (custom implementation), dedykowany SOC monitoring, Dedicated Support 24/7/365.

Warunki sovereign: Klient musi zapewnić: (a) infrastrukturę spełniającą minimalne wymagania hardware (AMD EPYC z SEV-SNP lub Intel Xeon z TDX, minimum 256 GB RAM per node, NVMe SSD, dedykowany HSM); (b) personel operacyjny przeszkolony przez SYLION (minimum 2 SRE + 2 SOC analysts); (c) compliance z wymaganiami bezpieczeństwa fizycznego data center (minimum Tier III).

Kontrakt STATE sprzedawany ze Szwajcarii lub USA, w zależności od jurysdykcji klienta i wymogów procedur zamówień publicznych.

14.10 Licencjonowanie hybrydowe

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Partner Wpływ na baseline: Średni Powiązane rozdziały: 14.1, 14.9, 16.10

Model hybrydowy: management plane hostowany przez SYLION (SaaS), data plane w infrastrukturze klienta. Dla organizacji wymagających suwerenności nad danymi, lecz bez kompetencji do zarządzania kompletną platformą.

14.11 Polityka upgrade/downgrade

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 14.2, 14.3, 14.6

Upgrade tieru: Klient może zmienić tier na wyższy w dowolnym momencie. Upgrade STANDARD→PRO: 3–7 dni roboczych, różnica cenowa naliczana prorata. Upgrade PRO→STATE: wymaga sovereign deployment planning, minimum 50 operatorów, 2–6 tygodni.

Downgrade tieru: Możliwy wyłącznie na koniec bieżącego okresu rozliczeniowego. Data portability gwarantowana — eksport danych w standardowych formatach (Matrix JSON, dokumenty oryginalne, audit trail CSV/JSON).

14.12 Polityka trial/pilot/POC

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Niski Powiązane rozdziały: 14.7, 16.2, 16.3

POC (managed, STANDARD/PRO): 30-dniowy proof of concept zarządzany przez zespół SYLION. Maksymalnie 10 operatorów. Pełna funkcjonalność wybranego tieru. Dedykowany inżynier wdrożeniowy. Koszt ryczałtowy, zaliczany na poczet kontraktu produkcyjnego.

Pilot (pre-production): 90-dniowy pilot, 10–50 operatorów. SLA ograniczone (99.5% vs produkcyjne 99.95%). Po pilocie: raport, plan migracji do produkcji, rekomendacja tieru.

Konwersja POC→pilot→produkcja: Ścieżka płynna — dane zachowane i zmigrowane, brak ponownego onboardingu.

Rozdział 15. KPI biznesowe i metryki sukcesu

15.1 Framework KPI — struktura i zasady

Status: [N] Normatywny Odbiorca: Zarząd | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 9.1–9.9, 15.2–15.10

System KPI SYLION jest zorganizowany w dziesięć kategorii metrycznych. KPI nie są jedynie narzędziem raportowym — stanowią mechanizm sterowania strategicznego: odchylenia od wartości docelowych uruchamiają zdefiniowane procesy eskalacyjne i korygujące.

Zasady frameworka KPI:

Mierzalność: Każdy KPI musi mieć precyzyjnie zdefiniowaną metodologię pomiaru, źródło danych i częstotliwość raportowania.

Odpowiedzialność: Każdy KPI ma jednego właściciela (owner) odpowiedzialnego za osiągnięcie wartości docelowej.

Kaskadowość: KPI strategiczne (raportowane zarządowi kwartalnie) dekomponują się na KPI operacyjne (raportowane team leadom tygodniowo), które dekomponują się na metryki techniczne (monitorowane w real-time).

Benchmarking: Każdy KPI porównywany z benchmarkiem branżowym (SaaS B2B, cybersecurity SaaS).

Review cadence: Strategiczne — kwartalnie. Operacyjne — tygodniowo. Techniczne — ciągły monitoring z alertami.

15.2 KPI strategiczne — cele z realnymi liczbami

Status: [N] Normatywny Odbiorca: Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 9.1–9.3, 15.1, 15.10

19.2.1 Cele Roku 1 — szczegółowy rozkład ARR

Segment	Tier	Operatorzy	Cena/op/mies.	MRR	ARR
Kancelarie prawne	STANDARD	30	400 €	12 000 €	144 000 €
Kancelarie prawne	PRO	10	1 500 €	15 000 €	180 000 €
Dziennikarze / politycy / NGO	PRO	10	1 500 €	15 000 €	180 000 €
Enterprise klasyczny	STANDARD	20	400 €	8 000 €	96 000 €
Subtotal STANDARD		50		20 000 €	240 000 €
Subtotal PRO		20		30 000 €	360 000 €
Pierwszy kontrakt STATE	STATE	50	2 500 €	125 000 €	1 500 000 €
TOTAL Rok 1		120		175 000 €	~2 100 000 €

Przychody dodatkowe Rok 1: - Hardware: 100 zestawów startowych × 1 250 € = 125 000 € jednorazowo - Professional services (wdrożenia, szkolenia): ~100 000–200 000 € - łączny przychód Rok 1 (subskrypcje + hardware + services): ~2,3–2,4 mln €

19.2.2 Cele Roku 3 — szczegółowy rozkład ARR

Segment	Tier	Operatorzy	Cena/op/mies.	MRR	ARR
Kancelarie prawne + enterprise	STANDARD	500	400 €	200 000 €	2 400 000 €
Dziennikarze / politycy / NGO / executive	PRO	200	1 500 €	300 000 €	3 600 000 €
3 kontrakty STATE (gov/defence)	STATE	150	2 500 €	375 000 €	4 500 000 €
TOTAL Rok 3		850		875 000 €	~10 500 000 €

19.2.3 KPI strategiczne — tabela docelowa

KPI	Definicja	Target Rok 1	Target Rok 3	Źródło danych
ARR (Annual Recurring Revenue)	Roczny przychód recurring z subskrypcji	~2,1 mln €	~10,5 mln €	Billing system
MRR (Monthly Recurring Revenue)	Miesięczny przychód recurring	~175 000 €	~875 000 €	Billing system

% ARR z tieru STATE	Udział przychodu recurring z tieru STATE	~71%	~43%	Billing system
Operatorzy aktywni	Łączna liczba aktywnych operatorów	120	850	Platform metrics
Kontrakty STATE	Liczba aktywnych kontraktów STATE	1	3	CRM
Certyfikaty bezpieczeństwa	Certyfikaty uzyskane	1 (ISO 27001)	3 (ISO + FIPS + CC)	Compliance tracker
Certified integrators	Partnerzy z certyfikatem	3	10+	Partner portal
Hardware kits sold	Zestawy startowe sprzedane	100	600+	Inventory system

Struktura ARR Rok 1 vs Rok 3:

W Roku 1 kontrakt STATE stanowi ~71% ARR (1,5 mln € z 2,1 mln €). Jest to celowe — jeden duży kontrakt stanowi fundament finansowy. W Roku 3 udział STATE spada do ~43% (4,5 mln € z 10,5 mln €), podczas gdy STANDARD i PRO rosną do 57% — oznacza to zdrową dywersyfikację przychodów.

Proces eskalacyjny: Jeśli KPI strategiczny odbiega o > 20% od wartości docelowej przez 2 kwartały z rzędu, zarząd musi podjąć decyzję korygującą: zmiana strategii, realokacja zasobów, pivot segmentowy lub rewizja targetu.

15.3 KPI sprzedażowe

Status: [N] Normatywny Odbiorca: Zarząd Wpływ na baseline: Wysoki Powiązane rozdziały: 10.7, 15.1, 15.2

KPI	Definicja	Target Rok 1	Benchmark (SaaS B2B)
ARR	Roczny przychód recurring	~2,1 mln €	N/A (early-stage)
NRR (Net Revenue Retention)	Retencja netto (expansion + churn)	> 110%	110–130% (best-in-class)
CAC (Customer Acquisition Cost)	Koszt pozyskania nowego klienta	< 30 000 € (STANDARD), < 100 000 € (STATE)	Varies by ACV
LTV (Lifetime Value)	Wartość klienta w cyklu życia	> 3× CAC	LTV/CAC > 3×
Win rate vs competitors	% wygranych deal-ów w competitive situations	> 50% (Faza 1 — brak bezpośredniej konkurencji EU)	25–35%
Sales cycle length	Średni czas od kontaktu do kontraktu	30d (PRO indywidualny), 60d (STANDARD), 180d (STATE)	90–180d (enterprise security)

LTV kalkulacja — klient STATE: - ARR: 1 500 000 € - Marża brutto: ~75% - Średni lifetime: 5 lat (government contracts) - LTV = 1 500 000 € × 75% × 5 = 5 625 000 € - CAC (szacowany): < 100 000 € (direct sales + POC) - LTV/CAC ratio: > 56×

LTV kalkulacja — klient PRO (dziennikarz/polityk): - ARR: 18 000 € (1 operator) - Marża brutto: ~94% - Średni lifetime: 3 lata - LTV = 18 000 € × 94% × 3 = 50 760 € - CAC (szacowany): < 5 000 € (organic/referral) - LTV/CAC ratio: > 10×

15.4 KPI adopcji

KPI adopcji mierzą skuteczność wdrożenia platformy przez operatorów i organizacje. Kluczowe metryki: Time-to-Active (czas od podpisania umowy do pierwszej aktywnej sesji operatora — target: <5 dni roboczych dla STANDARD, <10 dla PRO), Feature Adoption Rate (procent operatorów aktywnie korzystających z ≥3 workloadów — target: >60% po 30 dniach), Session Frequency (średnia liczba sesji na operatora na tydzień — sygnał rzeczywistego użycia vs licencja widmo).

Dodatkowe metryki adopcji: Operator Activation Rate (procent licencji z co najmniej jedną sesją w ciągu 30 dni — target: >80%), Onboarding Completion Rate (procent operatorów którzy ukończyli onboarding checklist — target: >95%), Support Ticket Rate (liczba ticketów na 100 operatorów na miesiąc — cel malejący: <5 po 3 miesiącach).

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Średni Powiązane rozdziały: 15.1, 16.2–16.4

KPI	Definicja	Target Rok 1	Częstotliwość
Operatorzy onboarded per miesiąc	Nowi operatorzy aktywowani	10+/miesiąc	Miesięcznie
Time-to-value	Czas od kontraktu do pierwszej sesji	< 3 dni (PRO indywidualny), < 10 dni (STANDARD), < 30 dni (STATE)	Per deployment
Feature utilization per tier	% funkcji aktywnie wykorzystywanych	> 60% after 90d	Kwartalnie
DAU/MAU ratio	Dzienni vs miesięczni aktywni	> 50%	Tygodniowo
POC→production conversion rate	% POC konwertowanych do produkcji	> 60%	Kwartalnie

15.5 KPI techniczne (sukces produktu)

KPI techniczne mierzą niezawodność i jakość platformy z perspektywy inżynierskiej. Dostępność platformy (uptime): target ≥99.5% dla STANDARD (8.7h downtime/rok), ≥99.9% dla PRO (4.4h/rok), ≥99.95% dla STATE (52min/rok). Mierzone per-gateway, per-środowisko operatora i per-warstwa (G1, G2, workload).

Session Quality Score (SQS): kompozytowa metryka jakości sesji obejmująca latencję round-trip (<150ms P95 dla Europy), jitter (<30ms P95), packet loss (<0.1%), czas nawiązania sesji (<3s P95). CDR Pipeline Throughput: czas przetwarzania pliku przez pipeline CDR — target P95 <500ms dla plików <10MB. Rebuild Time: czas odbudowy środowiska operatora po incydencie — target <15 minut.

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 15.1, 13.1–13.6

KPI	Definicja	Target	Źródło
Session availability	% czasu operatywności sesji pikselowej	99.5% (STANDARD), 99.95% (STATE)	99.9% (PRO), Monitoring
Mean time to provision	Czas provisioning nowego operatora (3 VPS)	< 15 min (automated)	Orchestrator
CDR processing latency	Czas CDR per-plik	< 30s (typowo), < 5 min (P99)	CDR metrics
Session latency (P95)	Opóźnienie sesji pikselowej	< 50ms (same region), < 150ms (cross-region)	Session metrics

Infrastructure cost per operator	Rzeczywisty koszt infra per operator	~66 € (bez Matrix), ~86 € (z Matrix)	Cloud billing
----------------------------------	--------------------------------------	--------------------------------------	---------------

15.6 KPI operacyjne

KPI operacyjne mierzą sprawność zespołów Operations, SRE i SOC. Mean Time to Detect (MTTD): średni czas od wystąpienia anomalii do wykrycia przez SIEM — target <5 minut dla alertów krytycznych (P1). Mean Time to Respond (MTTR): czas od wykrycia incydentu do podjęcia pierwszej akcji remediacyjnej — target <15 minut dla P1. Mean Time to Recover (MTTRec): czas od identyfikacji problemu do pełnego przywrócenia usługi — target <2h dla P1.

Dodatkowe metryki operacyjne: Change Failure Rate (procent zmian infrastruktury powodujących incydenty — target <5%), Deployment Frequency (liczba wdrożeń produkcyjnych na tydzień — wskaźnik dojrzałości DevSecOps), On-Call Alert Volume (liczba alertów poza godzinami pracy na inżyniera na tydzień — target <5 actionable alerts), Backup Verification Rate (procent backupów zweryfikowanych testowym przywróceniem — target 100% miesięcznie).

Status: [N] Normatywny Odbiorca: Zarząd | Infra | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 9.6, 15.1, 15.5

KPI	Definicja	Target	Benchmark
Uptime (platform)	Dostępność platformy	99.95% (min), 99.95% (STATE)	99.9–99.95% (enterprise SaaS)
MTTR	Średni czas od wykrycia do przywrócenia	< 30 min (P1), < 2h (P2)	< 1h (best-in-class)
Incident frequency (P1/P2)	Incydenty krytyczne per kwartał	< 2 P1/kw, < 8 P2/kw	Varies
Change failure rate	% deploymentów z degradacją	< 5%	< 15% (DORA benchmark)
RTO	Maksymalny czas odbudowy	< 4h (STD), < 1h (STATE)	4–24h (enterprise)
RPO	Maksymalna utrata danych	< 1h (STD), < 5 min (STATE)	1h–24h (enterprise)

15.7 KPI bezpieczeństwa

KPI bezpieczeństwa mierzą skuteczność mechanizmów ochronnych. Vulnerability Remediation SLA: krytyczne (CVSS ≥9.0) — patch w <24h, wysokie (7.0-8.9) — <72h, średnie (4.0-6.9) — <30 dni. Patch Compliance Rate: procent komponentów z aktualnym patching — target >99% dla krytycznych. Security Scan Coverage: procent workloadów objętych codziennym skanowaniem — target 100%.

Failed Authentication Rate: procent prób uwierzytelnienia zakończonych niepowodzeniem — wzrost o >200% względem baseline jest alertem. Privilege Escalation Attempts: liczba wykrytych prób nieautoryzowanej eskalacji uprawnień — target: 0 nieodkrytych. Audit Log Completeness: procent zdarzeń bezpieczeństwa objętych logowaniem — target 100%. Certificate Expiry Monitoring: liczba certyfikatów wygasających w <30 dni bez odnowienia — target 0.

Status: [N] Normatywny Odbiorca: Zarząd | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 9.4, 15.1

KPI	Definicja	Target	Źródło
MTTD	Średni czas wykrycia incydentu	< 15 min (automated), < 4h (manual)	SIEM
False positive rate	% alertów będących false positives	< 20%	SIEM tuning
Patch latency (critical CVE)	Czas od CVE do wdrożenia patcha	< 24h (critical), < 72h (high)	Vuln mgmt
Pentest findings (P1/P2)	Krytyczne/poważne findingsy per pentest	0 P1, < 3 P2 per annual pentest	Pentest reports
Security incident rate	Potwierdzone incydenty per kwartał	0 (target)	SOC

15.8 KPI wsparcia

KPI wsparcia mierzą jakość obsługi klienta i efektywność procesów wsparcia. Customer Satisfaction Score (CSAT): ocena satysfakcji po zamknięciu ticketu — target >4.2/5.0. First Contact Resolution Rate (FCR): procent ticketów rozwiązanych bez eskalacji — target >70%. SLA Compliance Rate: procent ticketów obsługiwanych w ramach SLA — target >98%.

Escalation Rate: procent ticketów eskalowanych do wyższego poziomu wsparcia — cel: malejący trend. Ticket Backlog Aging: procent ticketów otwartych >7 dni — target <10%. Knowledge Base Deflection Rate: procent zapytań rozwiązanych samodzielnie przez operatora za pomocą dokumentacji — wzrost tego wskaźnika oznacza dojrzewanie platformy i redukcję kosztów wsparcia.

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 14.8, 15.1

KPI	Definicja	Target	Benchmark
CSAT	Satysfakcja klienta (ankieta)	> 4.2/5.0	4.0–4.5 (enterprise SaaS)
Resolution time (P1)	Czas rozwiązania incydentu krytycznego	< 4h	4–8h (enterprise)
Resolution time (P2)	Czas rozwiązania incydentu poważnego	< 24h	24–48h
NPS	Net Promoter Score	> 40	30–50 (B2B SaaS)

15.9 KPI partnerskie

KPI partnerskie mierzą skuteczność ekosystemu partnerów wdrożeniowych i integracyjnych. Partner Revenue Share: przychód generowany przez kanał partnerski jako procent ARR — target Fazy 2: >30%. Certified Partner Count: liczba partnerów z aktywną certyfikacją SYLION — target rok 1: ≥3, rok 2: ≥8. Partner Deal Registration Rate: procent szans sprzedażowych zarejestrowanych przez partnerów — wskaźnik aktywności ekosystemu.

Partner Time-to-First-Deal: czas od certyfikacji partnera do pierwszego zamkniętego kontraktu — target <6 miesięcy. Partner NPS: Net Promoter Score wśród partnerów mierzony kwartalnie — target >40. Partner Onboarding Completion: procent zarejestrowanych partnerów którzy ukończyli pełen program certyfikacyjny — target >80%.

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Średni Powiązane rozdziały: 9.8, 15.1, 16.5–16.9

KPI	Definicja	Target Rok 1	Target Rok 3
Partner-sourced ARR %	Udział ARR z kanału partnerskiego	15%	35%
Active certified integrators	Partnerzy z certyfikatem	3	10+
Partner deal registration	Deal-e partnerskie per kwartał	5+/kw	20+/kw
Partner satisfaction (PSAT)	Satysfakcja partnerów	> 4.0/5.0	> 4.3/5.0

15.10 Dashboard zarządczy — widok zagregowany

Status: [R] Rekomendowany Odbiorca: Zarząd Wpływ na baseline: Średni Powiązane rozdziały: 15.1–15.9

Top 10 KPI (Executive Dashboard):

ARR — cel Rok 1: ~2,1 mln €, Rok 3: ~10,5 mln €

MRR — cel Rok 1: ~175 000 €/miesiąc

Operatorzy aktywni — cel Rok 1: 120, Rok 3: 850

Kontrakty STATE — cel Rok 1: 1, Rok 3: 3

Uptime — cel: 99.5% (STANDARD), 99.9% (PRO), 99.95% (STATE)

MTTD — cel: < 15 min (automated)

CSAT — cel: > 4.2/5.0

% ARR z STATE tier — Rok 1: ~71%, Rok 3: ~43%

Certification milestones — Rok 1: ISO 27001, Rok 2: FIPS 140-3, Rok 3: CC EAL4+

Security incident count — cel: 0

Dashboard generowany automatycznie z systemów źródłowych. Zarząd widzi stan platformy w jednym widoku — każdy KPI z: aktualną wartością, wartością docelową, trendem (↑↓→), statusem (zielony/żółty/czerwony).

Rozdział 16. Strategia wejścia na rynek i partnerstwa

16.1 Go-to-market — sekwencja trójfazowa

Status: [N] Normatywny Odbiorca: Zarząd | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 9.7, 11.1–11.8, 15.2

Strategia wejścia na rynek SYLION jest zaprojektowana jako trójfazowa ekspansja. Kolejność nie jest przypadkowa — każdy etap buduje referencje, certyfikacje i kompetencje niezbędne do wejścia na następny.

20.1.1 Faza 1: Europa (startuje teraz)

Segmenty docelowe: 1. Kancelarie prawne — poufność klienta, GDPR, wysokie ryzyko ataków celowanych, najwyższa WTP w segmencie komercyjnym 2. Dziennikarze śledczy — ochrona źródeł, aktorzy państwowi jako adwersarze, zbieżność z Freedom of Press Foundation 3. Politycy opozycji — aktywne ryzyko inwigilacji, obce wywiady, brak złożoności zamówień rządowych 4. NGO i organizacje praw człowieka operujące w wrogich środowiskach 5. Kadra zarządzająca high-risk — M&A, aktywizm inwestorski, board members

Dlaczego te segmenty w Fazie 1: - Mają natychmiastową potrzebę (nie „kiedyś”, lecz „teraz”) - Wysoką gotowość do zapłacenia premium (kancelarie, executive — trivialny koszt w kontekście budżetów) - Brak złożonego cyklu zamówień publicznych (kupują w dniach/tygodniach, nie miesiącach/latach) - Stanowią najlepsze referencje dla Fazy 2 (jeśli SYLION chroni dziennikarza przed Pegasusem → argument dla CISO; jeśli chroni kancelarię M&A → argument dla ministerstwa) - Budują wiarygodność na najtrudniejszych przypadkach użycia (state-level adversaries)

Cel Fazy 1: - 50 operatorów STANDARD (kancelarie + enterprise) = 20 000 €/miesiąc - 20 operatorów PRO (dziennikarze + politycy + executive) = 30 000 €/miesiąc - 100 zestawów hardware = 125 000 € jednorazowo - ISO 27001 — certyfikacja w trakcie

Model sprzedaży Faza 1: Direct sales z zespołem account executive + solution architect. Sprzedaż przez Swiss AG (klienci europejscy). Klienci prywatni (dziennikarze, politycy, NGO) — wyłącznie ze Szwajcarii.

20.1.2 Faza 2: Obronność i rząd (po certyfikacjach)

Wymagania wejścia: - ISO 27001 uzyskane (Rok 1) - FIPS 140-3 na ścieżce (Rok 2) - Common Criteria evaluation path zainicjowany (Rok 2–3) - Referencje z Fazy 1 — kancelarie, enterprise, media

Segmenty docelowe: - Defence-adjacent: kontrahenci wojskowi, konsultanci obronni, biura bezpieczeństwa parlamentarnego - Government: narodowe agencje cyberbezpieczeństwa, ministerstwa spraw zagranicznych, podmioty intelligence-adjacent (nie bezpośrednio wywiad — początkowo)

Harmonogram certyfikacji:

Certyfikacja	Timeline	Unlock
ISO 27001	Rok 1 (2026–2027)	Enterprise regulated, defence-adjacent
FIPS 140-3	Rok 2 (2027–2028)	Government, defence
Common Criteria EAL4+	Rok 3 (2028–2029)	National security agencies, NATO-adjacent

Cel Fazy 2: - 3 kontrakty STATE × 50 operatorów minimum = 375 000 €/miesiąc = 4 500 000 €/rok ARR - Minimum kontrakt STATE: 50 operatorów × 2 500 € = 125 000 €/miesiąc = 1,5 mln €/rok per klient

Model sprzedaży Faza 2: Direct sales z dedykowanym government sales team + partner system integrator. Kontrakty STATE sprzedawane ze Szwajcarii lub USA, w zależności od jurysdykcji klienta.

20.1.3 Faza 3: Rynek USA

Wymagania wejścia: - Europejskie referencje z Faz 1–2 - US LLC/Corp ustanowione - Partner US-based MSSP pozyskany

Segmenty docelowe: - Kancelarie prawne US — największy rynek prawny na świecie, First Amendment protection culture - Dziennikarze US — kultura ochrony źródeł, organizacje jak FPF - FedRAMP authorization jako cel długoterminowy (2–3 lata po wejściu europejskim)

Model sprzedaży Faza 3: Channel sales przez US-based MSSP partner + direct sales dla klientów strategic. Sprzedaż przez US LLC/Corp.

16.2 Faza POC — proof of concept

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 14.7, 14.12, 16.1

Cel POC: Demonstracja wartości platformy w kontekście specyficznym dla klienta. POC odpowiada na pytania: (a) Czy platforma spełnia wymagania bezpieczeństwa? (b) Czy UX jest akceptowalny? (c) Czy integracja z systemami klienta jest możliwa?

Struktura POC (30 dni): - Tydzień 1: Provisioning, konfiguracja, dostawa hardware (pakiet startowy 1 250 € × 10 operatorów) - Tydzień 2: Onboarding, szkolenie operatorów - Tydzień 3: Operacja w codziennych scenariuszach - Tydzień 4: Ewaluacja, raport techniczny, rekomendacje

Success criteria POC: (a) ≥ 80% operatorów ocenia UX jako „akceptowalny” lub „dobry”; (b) zero incydentów P1/P2; (c) session availability > 99.5%; (d) pozytywna ocena CISO/CTO/Managing Partnera; (e) deklaracja zainteresowania pilotem.

16.3 Faza pilot — pre-produkcja

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 14.12, 16.2, 16.4

Pilot: 10–50 operatorów, 90 dni, warunki zbliżone do produkcyjnych. SLA: 99.5% uptime. Testuje: skalowalność, procesy operacyjne, integrację, compliance, szkolenie personelu.

16.4 Faza produkcja

Status: [N] Normatywny Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 14.6, 15.5, 15.6, 16.3

Przebieg z pilota do produkcji jest formalnym gate'em wymagającym akceptacji obu stron. Checklist: raport pilotowy zaakceptowany, kontrakt podpisany (tier, operatorzy, SLA, billing), infrastruktura produkcyjna provisionowana (oddzielna od pilotowej), operatorzy zrekonfigurowani (nowe certyfikaty, nowe VPS), integracje aktywne, runbooki przekazane, szkolenie zakończone, acceptance test passed.

Odpowiedzialność operacyjna: SYLION odpowiada za: platformę, monitoring bezpieczeństwa (SOC), incident response, SLA. Klient odpowiada za: zarządzanie operatorami, polityki dostępu, compliance wewnętrzny, helpdesk L1 (jeśli nie managed service).

16.5 Partnerstwa technologiczne

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 9.8, 12.5, 16.1

Cloud providers (AMD SEV-SNP/Intel TDX): AWS (Nitro + SEV-SNP), Azure (DCasv5/ECasv5), GCP (Confidential VMs), OVHcloud, Hetzner. Priorytet: dostawcy europejscy (OVHcloud, Hetzner) dla Fazy 1, AWS/Azure dla Fazy 2–3 (gov/enterprise).

HSM vendors: Thales (Luna), Entrust (nShield), Utimaco. Integracja, certyfikacja kompatybilności, wspólne case studies. Dla wdrożeń sovereign: HSM on-premise FIPS 140-3 Level 3.

CDR technology partners: Votiro, OPSWAT, Glasswall. Krytyczny komponent pipeline'u transferu plików.

Matrix ecosystem: Element (Matrix) — partnerstwo na poziomie protokołu, upstream contributions, wczesny dostęp.

16.6 Partnerstwa wdrożeniowe

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Średni Powiązane rozdziały: 9.8, 15.9, 16.1

System integratorzy (SI): Firmy consultingowe z praktyką cybersecurity. Certyfikacja SYLION Integrator: szkolenie + egzamin + referencyjne wdrożenie. Revenue share na subskrypcji + marża na professional services.

MSSP (Managed Security Service Providers): Partnerzy zarządzający SYLION dla klientów końcowych. Per-tenant licensing, wielokliencka konsola zarządzania.

US-based MSSP (Faza 3): Kluczowy partner dla wejścia na rynek USA. Profil: doświadczenie FedRAMP, relacje z kancelariami i mediami US, zdolność distribution na rynku federalnym.

Compliance consultants: Gap analysis, przygotowanie compliance, wsparcie audytowe. Model: referral fee + joint workshops.

16.7 Partnerstwa compliance i audit

Status: [N] Normatywny Odbiorca: Zarząd | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 9.5, 15.2, 16.5

Certyfikacja jest strategicznym enablerem sprzedaży — segmenty Fazy 2 (government, defence-adjacent) wymagają certyfikacji jako warunku wejścia.

ISO 27001 — Rok 1: Partnerstwo z akredytowaną jednostką certyfikującą (BSI, TÜV, Bureau Veritas). Proces: 6–12 miesięcy. Realizacja w ramach Swiss AG. Fundament dla wszystkich kolejnych certyfikacji.

FIPS 140-3 — Rok 2: Partnerstwo z akredytowanym laboratorium (Leidos, atsec, UL Solutions). Proces: 12–18 miesięcy. Priorytet: moduł IPsec IKEv2 + HSM integration. Cel: Level 1 (software) → Level 2 (HSM boundary) → Level 3 (physical HSM).

Common Criteria — Rok 3: Partnerstwo z firmą CC (Riscure, Brightsight, TÜV IT). Proces: 18–24 miesiące. Cel: EAL4+ z augmentacjami ALC_FLR.3 + AVA_VAN.5.

FedRAMP — Rok 4+: Partnerstwo z 3PAO (Schellman, Coalfire, A-LIGN). Proces: 12–18 miesięcy + sponsor agency. Wymaga: US LLC/Corp, US-hosted infrastructure, US-based security team.

16.8 Strategia kanałowa

Status: [N] Normatywny Odbiorca: Zarząd | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 16.1, 16.6, 15.9

Direct sales (Faza 1 + STATE/SOVEREIGN): Klienci Fazy 1 (kancelarie, dziennikarze, politycy, executive) i klienci STATE obsługiwani bezpośrednio. Uzasadnienie: złożoność transakcji STATE, stawki kontraktowe (1,5 mln+ €/rok), potrzeba budowania bezpośredniego zaufania.

Channel sales (STANDARD, SMB): Od Fazy 2 — partnerzy kanałowi dla segmentu STANDARD. Niższe ACV nie uzasadnia direct sales.

Hybrid (PRO, regulated enterprise): SYLION prowadzi sprzedaż, partner wspiera wdrożenie i L1 support. Revenue share: 15–25% przychodu z subskrypcji dla partner-sourced deals.

Faza 3 (US): wyłącznie channel przez US-based MSSP partner.

16.9 Account-based strategy — Top 20 target accounts

Status: [R] Rekomendowany Odbiorca: Zarząd Wpływ na baseline: Średni Powiązane rozdziały: 11.2–11.6, 16.1, 16.8

Strategia ABM dla 20 najważniejszych kont docelowych Fazy 1. Kryteria selekcji: - Kancelarie prawne: top 50 kancelarii europejskich (Magic Circle, Silver Circle, wiodące kancelarie DACH, Nordics, Benelux) - Media: redakcje śledcze z udokumentowaną ekspozycją na ataki state-level - Politycy: europosłowie i parlamentarzyści krajowi z aktywnym profilem zagrożeń - Executive: zarządy firm w trakcie M&A, IPO, restrukturyzacji

Struktura planu per-account: (a) Account profile: organizacja, profil zagrożeń, current security stack (b) Decision map: decision-maker (Managing Partner / redaktor naczelny / polityk / CEO) (c) Value proposition: dostosowana do kontekstu (d) Engagement timeline: 7–90 dni od pierwszego kontaktu do kontraktu (e) Hardware requirement: ile zestawów startowych × 1 250 € (f) Tier recommendation: STANDARD (400 €) lub PRO (1 500 €)

16.10 Strategia sovereign i rządowa

Status: [N] Normatywny Odbiorca: Zarząd | Compliance | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 10.4, 11.7, 14.9, 16.1

Sektor sovereign i rządowy jest strategicznym segmentem docelowym SYLION — generuje najwyższe przychody per-klient (minimum 1,5 mln €/rok), buduje najsilniejsze referencje i wymaga najgłębszych kompetencji.

Data residency: SYLION gwarantuje rezydencję danych w kraju klienta. Serwery w lokalnym centrum danych, brak transferu danych poza granice, brak dostępu personelu spoza kraju (chyba że autoryzowany). Model: sovereign deployment z IaC, zarządzane przez lokalnego partnera pod nadzorem SYLION.

Local key management: Klucze w HSM zlokalizowanym w kraju klienta, pod kontrolą klienta. SYLION nigdy nie posiada kopii kluczy sovereign.

Kontrakty STATE ze Szwajcarii lub USA: W zależności od jurysdykcji klienta. Europejski klient → Swiss AG. Klient US → US LLC/Corp. Umożliwia to optymalizację jurysdykcyjną i compliance z lokalnymi wymogami zamówień.

Klienci prywatni (osoby fizyczne): Dziennikarze, politycy, NGO — obsługiwani wyłącznie ze Szwajcarii lub USA. Swiss AG zapewnia najwyższy poziom ochrony prywatności (nDSG/revDSG).

Reference customer strategy: Pierwsza referencja rządowa wymaga: (a) pricing concession (pilot pricing); (b) zaangażowanie C-level SYLION; (c) dedykowane zasoby wdrożeniowe; (d) gwarancje kontraktowe. Cel: pierwsza referencja rządowa w Roku 2 (defence-adjacent), pierwsza referencja ministry-level w Roku 3.

16.11 Strategia referencji i case studies

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner Wpływ na baseline: Średni Powiązane rozdziały: 16.1, 16.9, 16.10

Faza 1 — Anonimowe case studies (Rok 1): Pierwsi klienci mogą nie zgadzać się na ujawnienie nazwy. Case studies z anonimizacją: „Europejska kancelaria prawna, 50+ operatorów, tier STANDARD”, „Dziennikarz śledczy operujący w strefie konfliktu, tier PRO”. Zawartość: problem, rozwiązanie, wyniki (metryki), architektura (high-level).

Faza 2 — Named references (Rok 2+): Po zbudowaniu zaufania i sukcesach operacyjnych. Named reference jest najcenniejszym aktywem marketingowym — jeden znany klient rządowy lub duża kancelaria otwiera drzwi do dziesiątek podobnych organizacji.

Faza 3 — Reference visits (Rok 2+): Prospekt odwiedza istniejącego klienta. Autentyczność jest wartością.

Program referencyjny: Klienci uczestniczący otrzymują: zniżkę na subskrypcję (5–10%), priorytetowy dostęp do nowych funkcji, bezpośredni kanał do product management, zaproszenie na SYLION Customer Advisory Board.

Koniec Rozdziałów 8–16 Części II Księgi Systemu SYLION 3.0. # CZĘŚĆ III — WYMAGANIA, PRZYPADKI UŻYCIA I MODEL PRODUKTOWY

CZĘŚĆ III — WYMAGANIA I PRZYPADKI UŻYCIA

Rozdział 17. Wymagania wysokiego poziomu

17.1 Wymagania biznesowe

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 3.1, 5.2, 19.1, 23.1

Platforma SYLION musi realizować model multi-tenant, w którym każda organizacja (tenant) funkcjonuje jako odrębna, kryptograficznie izolowana jednostka operacyjna. Izolacja tenantów nie może opierać się wyłącznie na separacji logicznej warstwy aplikacyjnej — musi obejmować odrębne przestrzenie kluczy kryptograficznych zarządzane przez HSM, dedykowane środowiska workloadowe (namespace lub microVM per operator), odrębne polityki dostępu oraz fizycznie lub logicznie odseparowane ścieżki sieciowe w strefach Zone 3–5. Żaden tenant nie może uzyskać dostępu do zasobów, metadanych ani telemetrii innego tenanta, nawet w przypadku kompromitacji pojedynczego komponentu współdzielonego (np. G1).

Platforma musi obsługiwać trzy poziomy wdrożeniowe (STANDARD, PRO, STATE/SOVEREIGN), z których każdy definiuje inny profil bezpieczeństwa, dostępności i zgodności regulacyjnej. Poziom STANDARD zapewnia bazową ochronę dla organizacji komercyjnych; PRO dodaje zaawansowane mechanizmy (hardware attestation, BYOK, rozbudowany audyt); STATE/SOVEREIGN wymaga Confidential Computing, PQC, dedykowanego HSM on-premise oraz pełnej suwerenności infrastrukturalnej.

System musi generować logi zdarzeń gotowe do audytu (audit-ready) — każde zdarzenie bezpieczeństwa, decyzja polityki dostępu, operacja administracyjna i zmiana konfiguracji muszą tworzyć niemodyfikowalny rekord audytowy w Zone 4, eksportowalny do zewnętrznych systemów SIEM w formatach CEF i JSON-over-syslog.

Wdrożenie sovereign musi umożliwiać pełne działanie platformy na infrastrukturze kontrolowanej przez klienta — bez zależności od operatora SYLION po zakończeniu wdrożenia, z wyjątkiem opcjonalnych usług aktualizacji i wsparcia. Onboarding operatora (od momentu decyzji do pierwszej bezpiecznej sesji) musi zamknąć się w czasie poniżej 4 godzin, a pełny offboarding (rewokacja tożsamości, MFA, VPN, zniszczenie środowiska) — w czasie poniżej 15 minut.

Platforma nie może zależeć od jednego dostawcy chmury w zakresie funkcji certyfikowalnych (core functions). Każdy komponent krytyczny musi posiadać ścieżkę wdrożenia na minimum dwóch niezależnych dostawcach IaaS lub w wariantcie on-premise, co eliminuje ryzyko vendor lock-in i umożliwia suwerenne wdrożenia w jurysdykcjach z restrykcjami dotyczącymi lokalizacji danych.

17.2 Wymagania produktowe

Status: [N] Normatywny Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 4.1, 6.3, 18.1, 18.6, 22.2

Model Thin Client stanowi fundament architektury produktowej SYLION. Terminal operatora (Pixel z GrapheneOS lub zarządzany laptop) musi pełnić wyłącznie rolę urządzenia wyświetlającego — nie może przechowywać danych aplikacyjnych, historii komunikacji, kluczy kryptograficznych workloadów ani żadnych artefaktów sesji po jej zakończeniu. Jedyne dane trwałe na terminalu to: certyfikat klienta IPsec (odnawiany automatycznie), konfiguracja połączenia VPN oraz credentials FIDO2 w sprzętowym module bezpieczeństwa urządzenia (Titan M2 lub TPM).

Sesja zdalna musi wspierać następujące kanały interakcji: wyświetlanie tekstu i grafiki (pixel streaming), audio wejściowe i wyjściowe (mikrofon/głośnik z kodowaniem Opus lub równoważnym), wejście użytkownika (dotyk na urządzeniach mobilnych, klawiatura i mysz na laptopach) oraz kontrolowany schowek (clipboard). Polityka schowka musi być konfigurowalna per workload i per tier: w trybie STANDARD dopuszczalny schowek tekst-only między workloadami tego samego operatora; w trybie STATE/SOVEREIGN schowek między workloadami musi być domyślnie zablokowany.

Platforma musi obsługiwać minimum następujące typy workloadów: komunikacja Matrix (env-matrix) jako podstawowy kanał komunikacyjny, przeglądarka internetowa (env-browser) z egress proxy i filtrowaniem URL, dokumenty biurowe (env-office) z pełną obsługą formatów OOXML i ODF, komunikacja głosowa (env-voice) z szyfrowanym transportem, oraz opcjonalnie CRM (env-crm) i Signal jako workload kompatybilności (env-signal).

Transfer plików wchodzących do Zone 3 musi przechodzić przez mechanizm CDR (Content Disarm and Reconstruct). Proces CDR obejmuje: staging pliku w dedykowanej strefie buforowej, analizę i rekonstrukcję w efemerycznej microVM, usunięcie metadanych, dostarczenie zrekonstruowanego pliku wyłącznie do workloadu żądającego. Pełny audit trail transferu musi być generowany automatycznie.

Rewokacja sesji musi nastąpić w czasie poniżej 30 sekund od momentu podjęcia decyzji przez administratora — obejmuje to terminację tunelu IPsec, unieważnienie tokenu sesji w session broker oraz zamknięcie wszystkich aktywnych workloadów operatora.

17.3 Wymagania bezpieczeństwa

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 5.1, 6.1, 7.2, 18.3–18.5, 23.1

Architektura bezpieczeństwa SYLION opiera się na modelu Zero Trust, w którym żaden komponent — terminal, gateway, workload, usługa zarządzania — nie jest domyślnie zaufany. Każdy dostęp wymaga jednoczesnej weryfikacji trzech wymiarów: tożsamości operatora (uwierzytelnionej przez FIDO2/OIDC), stanu urządzenia (device posture — wersja OS, integralność konfiguracji, status certyfikatu) oraz oceny polityki kontekstowej (czas, lokalizacja sieciowa, profil ryzyka). Decyzja o dostępie jest podejmowana przez Policy Engine w G2 przy każdym żądaniu sesji — nie istnieje pojęcie „zaufanej sesji” trwającej bez rewalidacji.

Split Gateway G1/G2 musi działać na fizycznie odrębnych węzłach obliczeniowych lub w oddzielnych Trusted Execution Environments (TEE). G1 odpowiada wyłącznie za terminację transportu (IPsec/TLS) i inspekcję L3/L4 — nie ma wglądu w warstwę aplikacyjną. G2 odpowiada za egzekucję polityk aplikacyjnych, ocenę device posture i routing do workloadów. Separacja ta zapewnia, że kompromitacja G1 nie daje dostępu do polityk i danych sesji operatora.

Izolacja per-operator oznacza, że ruch sieciowy między środowiskami różnych operatorów jest domyślnie zablokowany. Nie istnieje ścieżka lateral movement bez jawnej, audytowalnej polityki. Każdy operator posiada dedykowaną przestrzeń (namespace lub microVM), z odrębnymi kluczami szyfrowania, politykami egress i profilem CDR.

Infrastruktura musi być niemutowalna (immutable): wszystkie komponenty muszą być wdrażalne z kodu (IaC — Terraform + Ansible). Czas pełnej odbudowy środowiska operatora z czystego stanu nie może przekroczyć 30 minut. Dryft konfiguracyjny musi być wykrywany automatycznie i sygnalizowany jako incydent

bezpieczeństwa.

CDR jest obowiązkowy: żaden plik nie może wejść do Zone 3 bez przejścia przez staging i przetworzenie CDR. Separacja management plane oznacza, że Zone 5 (zarządzanie platformą) musi być nieosiągalna z Zone 0 (terminal) i Zone 3 (workloady operatora) — zarówno sieciowo, jak i z perspektywy kontroli dostępu.

Confidential Computing (AMD SEV-SNP lub Intel TDX) jest wymagany dla workloadów Zone 3 w tierze STATE/SOVEREIGN, zapewniając ochronę danych w pamięci operacyjnej przed operatorem infrastruktury. FIDO2 jest obowiązkowy jako MFA dla wszystkich użytkowników STATE/SOVEREIGN; silnie rekomendowany dla PRO.

17.4 Wymagania operacyjne

Status: [N] Normatywny Odbiorca: Infra | SOC | Architekt | Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.1, 14.2, 21.1, 23.7

Platforma SYLION musi zapewniać dostępność mierzoną w modelu usługowym (service-level availability) z następującymi progami: STANDARD — 99,95% (dopuszczalny przestój ~4,4h/rok); PRO — 99,97%; STATE/SOVEREIGN — 99,95% (dopuszczalny przestój ~52 min/rok). Pomiar dostępności obejmuje zdolność operatora do nawiązania nowej sesji oraz kontynuacji istniejącej sesji — awaria pojedynczego workloadu nie wpływa na wskaźnik dostępności, o ile session broker zapewni restart w zdefiniowanym czasie.

Recovery Time Objective (RTO) musi wynosić poniżej 4 godzin dla STANDARD i poniżej 1 godziny dla STATE/SOVEREIGN. RTO obejmuje pełne przywrócenie zdolności operacyjnej tenanta — od wykrycia awarii, przez uruchomienie DR, po akceptację pierwszej sesji operatora. Recovery Point Objective (RPO) dla konfiguracji wynosi poniżej 24 godzin; klucze kryptograficzne workloadów nie podlegają backupowi (workloady są efemeryczne — klucze generowane dynamicznie z HSM).

Monitoring musi zapewniać, że wszystkie zdarzenia security-relevant dotrą do systemu SIEM w czasie poniżej 60 sekund od momentu wystąpienia. Obejmuje to: decyzje Policy Engine (allow/deny), zdarzenia sesji (connect/disconnect/timeout), zdarzenia CDR (accept/reject/quarantine), operacje administracyjne, alerty infrastrukturalne. Łańcuch telemetrii (agent → agregator → SIEM) musi być monitorowany pod kątem opóźnień i utraty zdarzeń.

Patch latency musi być zdefiniowany kontraktowo: krytyczne CVE (CVSS $\geq$ 9.0) — łatka wdrożona w produkcji w ciągu 24 godzin od publikacji patcha przez vendor; wysokie CVE (CVSS 7.0–8.9) — w ciągu 7 dni; średnie i niskie — zgodnie z harmonogramem release (maksymalnie 30 dni). Dla komponentów bez dostępnej łatki musi istnieć procedura kompensacyjna (virtual patching, izolacja, wyłączenie komponentu).

Provisioning nowego operatora musi zamykać się w 4 godzinach end-to-end: utworzenie tożsamości (IAM), przypisanie roli, enrollment MFA, przygotowanie terminala, provisioning VPN, utworzenie środowiska operatora, deployment workloadów, testy akceptacyjne. Proces musi być w co najmniej 80% zautomatyzowany (laC + API), z manualnymi krokami ograniczonymi do fizycznej konfiguracji terminala i weryfikacji tożsamości.

17.5 Wymagania integracyjne

Status: [N] Normatywny Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 9.3, 18.11, 18.15

Platforma SYLION musi oferować standardowe interfejsy integracyjne umożliwiające osadzenie w istniejącym ekosystemie IT klienta bez konieczności modyfikacji infrastruktury po stronie klienta. Integracja z zarządzaniem tożsamościami (IAM) musi wspierać protokoły OIDC (OpenID Connect), SAML 2.0 oraz federację LDAP/Active Directory. Federacja tożsamości oznacza, że operator uwierzytelnia się wobec IdP klienta (np. Azure AD, Okta, Keycloak), a SYLION otrzymuje token/assertion zawierający atrybuty niezbędne do ewaluacji polityki (rola, grupa, oddział, lokalizacja). Platforma nie może wymagać przechowywania hasel operatorów — uwierzytelnienie musi być delegowane do zewnętrznego IdP lub do mechanizmu FIDO2 zarządzanego lokalnie.

Eksport zdarzeń bezpieczeństwa do SIEM musi wspierać formaty branżowe: CEF (Common Event Format) dla integracji z ArcSight/QRadar, JSON-over-syslog (RFC 5424 + structured data) dla integracji z Splunk/Elasticsearch, oraz natywne konektory dla głównych platform SIEM (Splunk HEC, Sentinel Data Connector, QRadar Log Source). Eksport musi być konfigurowalny per tenant — administrator tenanta definiuje, które kategorie zdarzeń trafiają do jego SIEM, z zachowaniem rozdziału między telemetrią tenanta a telemetrią wewnętrzną SYLION.

API zarządzania musi być RESTful, wersjonowane (URL path versioning: /v1/, /v2/), zabezpieczone podwójnym mechanizmem: OAuth 2.0 (client credentials flow dla automatyzacji, authorization code flow dla interakcji administracyjnych) oraz mTLS (mutual TLS) jako wymaganie transportowe. API musi umożliwiać pełną automatyzację lifecycle operatora: provisioning, konfiguracja polityk, rewokacja, monitoring statusu — bez konieczności dostępu do konsoli administracyjnej.

Cała infrastruktura musi być wyrażalna jako moduły Terraform z pełną idempotencją. Nie może istnieć konfiguracja możliwa wyłącznie przez ręczną interwencję (no manual-only configuration). Moduły Terraform muszą być wersjonowane w repozytorium Git, z obowiązkowym peer review (PR) przed zastosowaniem w produkcji. State Terraform musi być przechowywany w encrypted backend z access control.

17.6 Wymagania deploymentowe

Status: [N] Normatywny Odbiorca: Architekt | Infra | Partner | Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 10.1, 19.3, 19.4

Platforma SYLION musi wspierać trzy modele wdrożeniowe, z których każdy odpowiada innemu profilowi kontroli i suwerenności. Model pierwszy — managed cloud — oznacza infrastrukturę zarządzaną i operowaną przez zespół SYLION na wybranej platformie IaaS; klient nie ma bezpośredniego dostępu do warstwy infrastrukturalnej, ale zachowuje pełną kontrolę nad konfiguracją polityk, workloadów i tożsamości swoich operatorów. Model drugi — customer-managed cloud — oznacza wdrożenie na koncie chmurowym klienta (AWS, GCP, Azure lub równoważny), przy czym SYLION dostarcza laC, obrazy i dokumentację; klient odpowiada za operację infrastruktury, SYLION zapewnia wsparcie L2/L3 i aktualizacje. Model trzeci — on-premise sovereign — oznacza pełne wdrożenie na sprzęcie fizycznym kontrolowanym przez klienta, bez jakiegokolwiek zależności runtime od zewnętrznych usług chmurowych; HSM musi być lokalny, łączność z Internetem opcjonalna (air-gap mode dla najwyższych wymagań).

Platforma nie może wymagać konkretnego dostawcy chmury dla funkcji certyfikowalnych (certifiable core). Certyfikowalny rdzeń obejmuje: G1, G2, session broker, Policy Engine, HSM integration, Zone 4 logging, IAM federation. Każdy z tych komponentów musi posiadać ścieżkę wdrożenia niezależną od dostawcy (provider-agnostic), co oznacza brak użycia usług managed specyficznych dla dostawcy (np. AWS KMS jako jedyny backend HSM) w ścieżce certyfikacyjnej. Usługi managed mogą być wykorzystywane jako opcja convenience w modelu managed cloud, ale nie jako jedyna implementacja.

Wdrożenie multi-region musi zachowywać ograniczenia rezydencji danych per tenant. Oznacza to, że dane operatora (workloady, logi, klucze) muszą rezydować wyłącznie w regionie zdefiniowanym w konfiguracji tenanta. Ruch między regionami ograniczony jest do metadanych operacyjnych (health checks, metryki

zagregowane bez danych treściowych, replikacja konfiguracji). Konfiguracja rezydencji musi być audytowalna — każda zmiana regionu generuje rekord w Zone 4 z wymogiem autoryzacji dual-approval.

17.7 Wymagania observability

Status: [N] Normatywny Odbiorca: Infra | SOC | Architekt | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 14.1, 18.14, 23.1, 23.7

Observability platformy SYLION opiera się na trzech filarach, z których każdy musi spełniać wymagania zarówno operacyjne, jak i bezpieczeństwa.

Filar 1 — Logi. Wszystkie logi muszą być strukturyzowane (JSON), niemodyfikowalne (WORM — Write Once Read Many) i przechowywane w Zone 4. Strukturyzacja oznacza, że każdy rekord zawiera minimum: timestamp (UTC, synchronizowany NTP z tolerancją <1s), source component, event type, severity, tenant ID (jeśli dotyczy), operator ID (jeśli dotyczy), correlation ID. Logi bezpieczeństwa muszą być podpisywane łańcuchem hashów (hash chain) zapewniającym wykrywalność manipulacji. Retencja: minimum 2 lata dla logów bezpieczeństwa, minimum 1 rok dla logów operacyjnych.

Filar 2 — Metryki. System musi eksponować metryki real-time w formacie Prometheus-compatible (OpenMetrics). Metryki krytyczne obejmują: latencję sesji (P50, P95, P99), throughput G1/G2, wykorzystanie zasobów workloadów, status HA komponentów, kolejkę CDR, liczbę aktywnych sesji per tenant. Alerting musi być skonfigurowany dla każdej metryki krytycznej z progami zdefiniowanymi per tier (np. latencja P99 > 100ms dla STATE = alert).

Filar 3 — Trace'y. Distributed tracing musi obejmować pełną ścieżkę żądania: terminal → G1 → G2 → session broker → workload, z propagacją correlation ID. Trace'y bezpieczeństwa (security-relevant) muszą zawierać decyzje Policy Engine, wyniki device posture evaluation, zdarzenia CDR. Format: OpenTelemetry (OTLP).

Telemetria musi być tenant-aware: administrator tenanta widzi aktywność swoich operatorów, ale nie widzi telemetrii innych tenantów ani telemetrii wewnętrznej SYLION. Operatorzy SYLION (zespół infrastrukturalny) widzą metryki zagregowane i logi infrastrukturalne, ale nie mają dostępu do treści komunikacji operatorów ani szczegółów sesji wykraczających poza parametry techniczne. Ta separacja prywatności musi być wymuszona architektonicznie (odrębne pipeline'y telemetrii), nie tylko proceduralnie.

Telemetria bezpieczeństwa nie może zawierać danych treściowych tenanta — logujemy „operator X wysłał plik o hash Y do workloadu Z”, ale nie logujemy zawartości pliku ani treści wiadomości.

17.8 Wymagania zgodności

Status: [N] Normatywny Odbiorca: Compliance | Zarząd | Architekt | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 11.1, 23.3, 23.8

Platforma SYLION musi spełniać wymagania GDPR w zakresie minimalizacji danych (data minimization): zbierane i przetwarzane mogą być wyłącznie dane niezbędne do świadczenia usługi bezpieczeństwa i operacji platformy. Oznacza to: tożsamość operatora (identyfikator, rola, przynależność organizacyjna), metadane sesji (czas, czas trwania, źródłowy adres sieciowy — zanonimizowany po okresie retencji operacyjnej), zdarzenia bezpieczeństwa (decyzje polityk, zdarzenia CDR, alerty), metryki operacyjne. Treść komunikacji (wiadomości Matrix, dokumenty, dane CRM) nie jest przetwarzana ani dostępna dla SYLION — E2EE zapewnia, że platforma technicznie nie ma zdolności odczytu.

Audit trail musi spełniać wymóg kompletności: każda uprzywilejowana akcja (privileged action) musi generować niemodyfikowalny rekord audytowy zawierający: timestamp (UTC, hash-chain linked), identyfikator aktora (administrator, system automatyczny), identyfikator celu (operator, zasób, polityka), opis akcji, wynik (success/failure), łańcuch zatwierdzenia (approval chain, jeśli dotyczy). Rekord musi być zapisany w Zone 4 przed potwierdzeniem wykonania akcji (write-ahead audit).

Rezydencja danych musi być konfigurowalna per tenant z granularnością do poziomu regionu (np. EU, PL-only, DE-only). Konfiguracja rezydencji jest wiążąca — platforma musi technicznie uniemożliwić przechowywanie lub przetwarzanie danych tenanta poza skonfigurowanym regionem. Weryfikacja rezydencji musi być audytowalna (raporty potwierdzające, że żadne dane nie opuściły regionu).

Prawo do usunięcia (Right to Erasure, Art. 17 GDPR) musi być realizowalne poprzez zdefiniowany proces: żądanie usunięcia → weryfikacja tożsamości żądającego → identyfikacja wszystkich danych operatora/tenanta → usunięcie danych operacyjnych (retencja logów bezpieczeństwa może podlegać wyjątkowi z Art. 17(3)(e)) → wygenerowanie dowodu usunięcia (evidence of deletion) z hashami potwierdzającymi, że dane zostały nadpisane lub zniszczone kryptograficznie (crypto-shredding przez zniszczenie klucza szyfrującego). Cały proces musi być zakończony w ciągu 30 dni od żądania.

17.9 Wymagania testowe

Status: [N] Normatywny Odbiorca: Dev | SOC | Compliance | Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 14.3, 19.5, 23.7

Testowanie bezpieczeństwa platformy SYLION musi obejmować wielowarstwowy program weryfikacji obejmujący testy automatyczne, manualne i niezależne audyty. Testy penetracyjne muszą być przeprowadzane minimum raz w roku przez niezależny podmiot zewnętrzny (nie powiązany kapitałowo z SYLION). Zakres penetration testu musi obejmować: zewnętrzny perimeter (G1, endpointy publiczne), wewnętrzną segmentację (lateral movement między strefami), izolację tenantów (próba dostępu do danych innego tenanta), eskalację uprawnień (od operatora do admina, od admina do management plane), bezpieczeństwo supply chain (integralność obrazów, pipeline CI/CD). Wyniki muszą być raportowane z klasyfikacją CVSS i planem remediacji z terminami zgodnymi z polityką patch latency.

Testowanie dostępności obejmuje ćwiczenia Disaster Recovery (DR), które muszą być przeprowadzane minimum raz na kwartał. Każde ćwiczenie DR musi obejmować: symulację awarii regionalnej (failover do regionu zapasowego), weryfikację RTO (czy sesje operatorów wracają w zdefiniowanym czasie), weryfikację RPO (czy konfiguracja jest aktualna), test procedury break-glass (dostęp awaryjny do management plane), test odbudowy środowiska operatora z czystego stanu. Wyniki ćwiczeń muszą być dokumentowane i przechowywane jako evidence audytowe.

Regresja funkcjonalna musi być w pełni zautomatyzowana i musi przejść pomyślnie przed każdym wdrożeniem produkcyjnym. Pipeline CI/CD musi zawierać: testy jednostkowe (unit), testy integracyjne (component interaction), testy end-to-end (pełna ścieżka operator → G1 → G2 → workload), testy bezpieczeństwa (SAST, DAST, dependency scanning), testy wydajności (latency benchmarks). Gate: żaden artefakt nie trafia do produkcji bez 100% pass rate na testach krytycznych.

Testowanie polityk stanowi wymóg odrębny: każda zmiana polityki dostępu (w Policy Engine/G2) musi posiadać towarzyszący test automatyczny weryfikujący zarówno pozytywny case (dostęp przyznany prawidłowo), jak i negatywny case (dostęp odmówiony prawidłowo). Testy polityk muszą być uruchamiane w pipeline przed wdrożeniem zmiany — polityka bez testu nie może być wdrożona.

Rozdział 18. Wymagania szczegółowe według obszarów

18.1 Wymagania dla terminala operatora

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 4.1, 17.2, 20.1, 22.2

Terminal operatora stanowi jedyny punkt styku użytkownika z platformą SYLION i jako taki musi spełniać rygorystyczne wymagania bezpieczeństwa przy jednoczesnym zachowaniu użyteczności.

REQ-TRM-001 — Pamięć masowa terminala musi być szyfrowana pełnym szyfrowaniem dysku (FDE) z kluczem powiązanym ze sprzętowym modulem bezpieczeństwa (Titan M2 na Pixel, TPM 2.0 na laptopie). Szyfrowanie musi być aktywne w stanie spoczynku i nie może być wyłączalne przez użytkownika.

REQ-TRM-002 — System operacyjny terminala mobilnego musi być GrapheneOS w wersji aktualnej (maksymalnie 7 dni od publikacji aktualizacji). Dla terminali laptopowych dopuszczalny jest hardened Linux (np. Fedora Silverblue) lub Windows z profilem CIS Benchmark Level 2.

REQ-TRM-003 — Na terminalu nie mogą być instalowane aplikacje poza zatwierdzoną listą (allowlist). Zarządzanie listą musi odbywać się centralnie poprzez profil MDM lub policy management.

REQ-TRM-004 — Terminal musi wymuszać ekran blokady z timeout ≤ 2 minuty. Odblokowanie wymaga biometrii lub PIN ≥ 6 cyfr.

REQ-TRM-005 — Terminal musi obsługiwać FIDO2/WebAuthn z kluczem sprzętowym (YubiKey, wbudowany Titan M2). Terminal, który nie wspiera FIDO2, nie może być używany w tierze STATE/SOVEREIGN.

REQ-TRM-006 — Terminal musi wspierać hardware attestation (Android Key Attestation lub równoważny) umożliwiający G2 weryfikację integralności urządzenia przed przyznaniem sesji.

REQ-TRM-007 — Na terminalu nie mogą pozostawać żadne dane workloadowe po zakończeniu sesji. Klient SYLION musi implementować czyszczenie pamięci podręcznej po rozłączeniu.

REQ-TRM-008 — Terminal musi obsługiwać zdalne wymazanie (remote wipe) inicjowane przez management plane. Wipe musi obejmować: rewokację certyfikatu IPsec, usunięcie profilu VPN, reset konfiguracji SYLION.

REQ-TRM-009 — Schowek (clipboard) terminala musi być kontrolowany przez politykę: kopiowanie tekstu z workloadu do terminala wymaga jawnego zezwolenia polityki; domyślnie zablokowane w STATE/SOVEREIGN.

REQ-TRM-010 — Zrzuty ekranu (screenshot, screen recording) muszą być kontrolowalne: blokada na poziomie OS (GrapheneOS DRM flag) dla STATE/SOVEREIGN; logowanie prób dla PRO.

18.2 Wymagania dla routera dostępowego

Status: [N] Normatywny Odbiorca: Architekt | Infra | Dev Wpływ na baseline: Krytyczny Powiązane rozdziały: 4.2, 17.3, 18.3

Router dostępowy (lub klient VPN wbudowany w terminal) pełni funkcję bramki kryptograficznej po stronie operatora, zapewniając, że cały ruch organizacyjny przechodzi przez tunel IPsec.

REQ-RTR-001 — Router musi implementować klienta IPsec IKEv2 z uwierzytelnieniem certyfikatem mTLS. Certyfikat klienta musi być przechowywany w sprzętowym module bezpieczeństwa (TPM, Titan M2, Secure Enclave) i nie może być eksportowalny.

REQ-RTR-002 — Router musi implementować kill switch: w przypadku utraty tunelu IPsec, cały ruch sieciowy (z wyjątkiem ruchu niezbędnego do renegotiacji tunelu) musi być blokowany. Żaden ruch organizacyjny nie może wyciec poza tunel.

REQ-RTR-003 — Split DNS musi być skonfigurowany tak, aby wyłącznie zapytania DNS dotyczące domen organizacyjnych (zdefiniowanych w polityce) były kierowane przez tunel. Pozostałe zapytania DNS mogą korzystać z lokalnego resolvera, o ile polityka tieru na to zezwala (w STATE/SOVEREIGN cały DNS musi iść przez tunel).

REQ-RTR-004 — Lokalny firewall terminala musi blokować cały ruch wychodzący nie przechodzący przez tunel IPsec (z wyjątkiem ruchu konfiguracyjnego i usług systemowych zdefiniowanych w allowliście). Reguły firewall muszą być zarządzane centralnie i nie mogą być modyfikowalne przez operatora.

REQ-RTR-005 — Router musi wspierać detekcję manipulacji konfiguracją (tamper detection). Każda zmiana konfiguracji VPN musi być logowana i raportowana do management plane. Konfiguracja musi być podpisana cyfrowo — router odrzuca konfigurację z nieprawidłowym podpisem.

REQ-RTR-006 — Konfiguracja routera musi być zarządzana centralnie (push from management plane) z wersjonowaniem. Operator nie może ręcznie modyfikować parametrów tunelu, algorytmów kryptograficznych ani endpointów.

REQ-RTR-007 — Wersja konfiguracji musi być przypięta (pinned) — router akceptuje wyłącznie konfigurację z wersją równą lub nowszą niż aktualnie zainstalowana, co zapobiega atakom rollback.

REQ-RTR-008 — Router musi wspierać automatyczne przełączanie między interfejsami sieciowymi (Wi-Fi → LTE/5G) z zachowaniem sesji IKEv2 (MOBIKE — RFC 4555). Przełączenie musi być transparentne dla sesji workloadu.

18.3 Wymagania dla warstwy transportowej

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 5.3, 17.3, 18.2, 18.4

Warstwa transportowa SYLION opiera się na protokole IPsec z IKEv2, wybranym ze względu na dojrzałość kryptograficzną, wsparcie dla certyfikatów X.509, kompatybilność z modułami FIPS i natywną obsługę w systemach operacyjnych.

REQ-TRN-001 — Transport musi wykorzystywać IKEv2 (RFC 7296) z uwierzytelnianiem EAP-TLS (RFC 5216) lub certyfikatami X.509. Uwierzytelnianie PSK (Pre-Shared Key) jest zabronione.

REQ-TRN-002 — Algorytm szyfrowania: AES-256-GCM (RFC 4106) jako jedyny dopuszczalny algorytm symetryczny. AES-128 i ChaCha20 nie są dopuszczalne w ścieżce produkcyjnej.

REQ-TRN-003 — Algorytm integralności: SHA-384 (HMAC-SHA-384 dla IKE SA, implicit w GCM dla ESP). SHA-256 dopuszczalny jako fallback wyłącznie dla kompatybilności z legacy — wymaga udokumentowanego wyjątku.

REQ-TRN-004 — Grupa Diffie-Hellman: minimum DH Group 20 (ECP-384, NIST P-384). Grupy poniżej 384-bit (Group 14, Group 19) nie są dopuszczalne. Dla STATE/SOVEREIGN rekomendowane Group 21 (ECP-521).

REQ-TRN-005 — Perfect Forward Secrecy (PFS) jest obowiązkowe. Rekeying Child SA musi następować z nową wymianą DH, nie wyłącznie przez derivację z IKE SA.

REQ-TRN-006 — Implementacja musi być walidowana FIPS 140-3. Referencyjne wdrożenie: strongSwan na RHEL 9 lub Ubuntu 22.04+ z modułem kryptograficznym FIPS (libgcrypt-fips lub OpenSSL FIPS provider). Każda inna implementacja wymaga udokumentowanej walidacji.

REQ-TRN-007 — SA lifetime: IKE SA maximum 24 godziny, Child SA (ESP) maximum 8 godzin lub 1 GB danych — co nastąpi pierwsze. Po przekroczeniu lifetime następuje rekeying, nie rozłączenie.

REQ-TRN-008 — Dead Peer Detection (DPD, RFC 3706): aktywny, interwał ≤ 30 sekund, timeout $\leq 3 \times$ interwał. Po wykryciu martwego peera — natychmiastowa terminacja SA i logowanie zdarzenia.

REQ-TRN-009 — Anti-replay: okno anti-replay minimum 64 pakiety (rekomendowane 128). Anti-replay musi być włączone i nie może być wyłączane.

REQ-TRN-010 — NAT-Traversal (NAT-T, RFC 3948): musi być obsługiwane dla środowisk za NAT. Enkapsulacja UDP/4500 aktywowana automatycznie po wykryciu NAT.

18.4 Wymagania dla G1

Status: [N] Normatywny Odbiorca: Architekt | Infra | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 5.1, 17.3, 18.3, 18.5

Gateway G1 stanowi pierwszą linię obrony platformy SYLION — punkt terminacji transportu kryptograficznego i filtracji ruchu na warstwie sieciowej. G1 celowo nie posiada wglądu w warstwę aplikacyjną, co minimalizuje powierzchnię ataku.

REQ-G1-001 — G1 musi wykonywać stateful packet inspection na warstwach L3/L4 (IP, TCP/UDP, ICMP). Inspekcja warstwy aplikacyjnej (L7) jest zabroniona na G1 — pełni ją G2.

REQ-G1-002 — Rate limiting musi być konfigurowalny per-source IP i per-Security Association (SA). Limity domyślne: 10 000 pakietów/s per SA, 100 nowych połączeń/s per source IP. Przekroczenie limitu: drop z logowaniem.

REQ-G1-003 — G1 musi implementować mechanizmy anti-DDoS: SYN cookies (RFC 4987), limity połączeń per source, blackholing source IP po przekroczeniu progu alertu. Progi muszą być konfigurowalne i monitorowane.

REQ-G1-004 — G1 terminuje wyłącznie transport TLS/IPsec. Nie przetwarza payloadu aplikacyjnego — po terminacji transportu, ruch jest przekazywany do G2 poprzez wewnętrzny kanał (wireline Zone 1 → Zone 2) z zachowaniem szyfrowania hop-to-hop.

REQ-G1-005 — G1 musi być wdrażany jako infrastruktura niemutowalna (immutable). Żaden stan persystentny (logi tymczasowe, cache) nie może przetrwać restartu. Logi muszą być streamowane w real-time do Zone 4.

REQ-G1-006 — Każda próba połączenia (zarówno udana, jak i odrzucona) musi generować rekord audytowy zawierający: timestamp, source IP (zahashowane lub pełne — zależnie od polityki prywatności), destination port, SA identifier, wynik (accept/reject/rate-limit), powód odrzucenia.

REQ-G1-007 — G1 musi działać w konfiguracji HA minimum active-passive. Failover time: < 5 sekund. Health check: co 2 sekundy. Stan SA musi być synchronizowany między węzłami HA (IKEv2 SA sync lub fast re-establishment).

REQ-G1-008 — Czas pełnej odbudowy G1 z czystego stanu (nowa instancja z obrazu IaC) nie może przekroczyć 10 minut. Obejmuje to: provisioning VM/bare-metal, deployment konfiguracji, załadowanie certyfikatów, weryfikację health check.

REQ-G1-009 — G1 musi eksponować metryki operacyjne: active SA count, packets/s, connections/s, drop rate, CPU/memory utilization, latencja terminacji TLS/IPsec.

18.5 Wymagania dla G2

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 5.2, 17.3, 18.4, 18.6, 23.1

Gateway G2 stanowi centralny punkt egzekucji polityk bezpieczeństwa platformy SYLION. W odróżnieniu od G1, G2 operuje na warstwie aplikacyjnej i podejmuje kontekstowe decyzje o dostępie.

REQ-G2-001 — G2 musi egzekwować polityki dostępu na warstwie aplikacyjnej, uwzględniając: tożsamość operatora (z IAM/IdP), device posture (wynik oceny z hardware attestation, wersja OS, compliance status), żądany zasób (workload, akcja), kontekst (czas, lokalizacja sieciowa, risk score).

REQ-G2-002 — Device posture evaluation musi obejmować minimum: weryfikację wersji OS terminala, status szyfrowania dysku, obecność wymaganego klienta bezpieczeństwa, ważność certyfikatu klienta, wynik hardware attestation (jeśli obsługiwany). Wynik oceny: score numeryczny 0–100 z progami per tier (np. STATE wymaga ≥ 90).

REQ-G2-003 — Mapowanie operator-to-environment musi być deterministyczne i audytowalne. Operator X z rolą Y w tenancie Z zawsze trafia do tego samego środowiska workloadowego. Mapowanie jest definiowane w polityce, nie wynika z logiki runtime.

REQ-G2-004 — G2 musi wyzwać proces CDR dla każdego transferu pliku wchodzącego do Zone 3. Decyzja CDR (accept/reject/quarantine) musi być logowana z pełnym kontekstem (operator, plik hash, typ, źródło, workload docelowy).

REQ-G2-005 — Latencja decyzji polityki: P99 < 10ms. Oznacza to, że 99% decyzji allow/deny musi być podjętych w czasie poniżej 10 milisekund od momentu otrzymania żądania. Wymaganie to narzuca cache'owanie polityk lokalnie na G2 z invalidacją event-driven.

REQ-G2-006 — Wszystkie decyzje G2 (allow, deny, step-up auth, redirect to CDR) muszą być logowane do Zone 4 w formacie strukturyzowanym, z correlation ID umożliwiającym powiązanie z sesją operatora i trace'em end-to-end.

REQ-G2-007 — G2 musi działać w konfiguracji HA active-active. Load balancing: per-session affinity (nie per-packet). Failover: seamless — utrata jednego węzła G2 nie terminuje istniejących sesji obsługiwanych przez pozostałe węzły.

REQ-G2-008 — Policy hot-reload: zmiana polityki musi być aplikowalna bez przerywania istniejących sesji. Nowa polityka obowiązuje dla nowych żądań; istniejące sesje mogą kontynuować z dotychczasową polityką do momentu re-evaluacji (przy następnym żądaniu zasobu lub po upływie TTL polityki).

REQ-G2-009 — G2 musi wspierać step-up authentication: jeśli polityka wymaga wyższego poziomu uwierzytelnienia (np. FIDO2 re-auth dla dostępu do wrażliwego workloadu), G2 musi przekierować operatora do procesu step-up bez terminacji sesji bazowej.

18.6 Wymagania dla session broker

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 6.1, 17.2, 18.5, 20.2, 22.2

Session broker zarządza cyklem życia sesji zdalnej operatora — od momentu autoryzacji przez G2 do zakończenia sesji. Broker odpowiada za publikację aplikacji, izolację sesji i egzekucję polityk sesyjnych.

REQ-SBR-001 — Domyślnym trybem publikacji musi być app-only publishing (publikacja pojedynczych aplikacji/workloadów), nie pełny pulpit (full desktop). Operator widzi okno Matrix, okno przeglądarki, okno Office — nie widzi pulpitu systemu operacyjnego workloadu. Full desktop jest dopuszczalny wyłącznie jako udokumentowany wyjątek dla specyficznych wymagań.

REQ-SBR-002 — Token sesji musi mieć ograniczony czas życia: maximum 8 godzin. Po upływie TTL operatora wymaga się ponownego uwierzytelnienia (re-auth). Dla STATE/SOVEREIGN TTL może być skrócony do 4 godzin.

REQ-SBR-003 — Broker musi egzekwować politykę schowka (clipboard) per workload: text-only, text+images, full, disabled. Domyślnie dla STATE/SOVEREIGN: disabled między workloadami różnych klas bezpieczeństwa.

REQ-SBR-004 — Polityka zrzutów ekranu (screen capture) musi być egzekwowalna: broker może ustawiać flagi DRM na strumieniu pikselowym, uniemożliwiając przechwycenie przez system operacyjny terminala (GrapheneOS respektuje te flagi).

REQ-SBR-005 — Polityka drukowania: domyślnie wyłączone w STATE/SOVEREIGN, konfigurowalne w STANDARD/PRO. Drukowanie wymaga przejścia pliku przez CDR staging.

REQ-SBR-006 — Izolacja per-session: stan jednej sesji (pamięć, tokeny, kontekst) nie może wyciec do innej sesji tego samego operatora ani innego operatora. Każda sesja działa w odizolowanym kontekście.

REQ-SBR-007 — Session recording (nagrywanie sesji) musi być obsługiwane jako opcja konfigurowalna per tenant i per rola. Recording musi być jawne (operator widzi indykator nagrywania). Dane recording przechowywane w Zone 4, dostępne wyłącznie dla audytorów z uprawnieniem.

REQ-SBR-008 — Session audit log musi rejestrować: start sesji (operator, terminal, workload), zdarzenia sesji (idle, active, clipboard event, file transfer, reconnect), koniec sesji (powód: user logout, timeout, admin revoke, heartbeat failure, error).

REQ-SBR-009 — Broker musi wspierać graceful reconnect: w przypadku krótkotrwałego zerwania połączenia (< 60s), sesja musi być zachowana i dostępna do ponownego podłączenia bez pełnego re-auth (z weryfikacją session token).

18.7 Wymagania dla workloadów operatorów

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 6.3, 17.3, 18.9, 21.3

Workloady operatorów stanowią izolowane środowiska wykonawcze, w których działają aplikacje dostępne przez pixel streaming. Każdy workload musi spełniać wymagania izolacji, hardening i observability.

REQ-WKL-001 — Workload musi działać jako rootless container lub microVM, w zależności od tieru i poziomu ryzyka. MicroVM (Firecracker) jest obowiązkowa dla: env-signal, workloadów STATE/SOVEREIGN, workloadów przetwarzających dane zewnętrzne. Container (rootless, z gVisor lub kata-containers jako runtime) jest dopuszczalny dla STANDARD/PRO workloadów niskiego ryzyka.

REQ-WKL-002 — Każdy workload musi działać w dedykowanym namespace Kubernetes z network policies blokującymi ruch do namespaces innych operatorów. Ruch między workloadami tego samego operatora podlega polityce (domyślnie: deny all, allow explicit).

REQ-WKL-003 — Profil bezpieczeństwa musi obejmować: seccomp (whitelist syscalli), AppArmor lub SELinux (mandatory access control), drop all capabilities z wyjątkiem jawnie wymaganych. Profil musi być zdefiniowany per typ workloadu i audytowalny.

REQ-WKL-004 — Workload nie może posiadać capabilities: NET_RAW, SYS_ADMIN, SYS_PTRACE (z wyjątkiem debugowania w środowisku dev — nigdy w produkcji). Lista dozwolonych capabilities musi być minimalnym zestawem.

REQ-WKL-005 — Egress whitelist jest obowiązkowy: każdy workload posiada jawnie zdefiniowaną listę dozwolonych celów wychodzących (np. env-browser: egress proxy; env-signal: Signal Foundation ASN; env-matrix: wewnętrzny homeserver). Ruch do celów spoza whitelist jest blokowany i logowany.

REQ-WKL-006 — Workload musi być odbudowywany (rebuild from image) po każdej wykrytej anomalii: nieautoryzowany syscall, próba eskalacji uprawnień, nietypowy wzorec ruchu sieciowego. Odbudowa jest automatyczna i nie wymaga interwencji admina.

REQ-WKL-007 — Storage workloadu musi być szyfrowany kluczem per-workload, generowanym dynamicznie z HSM. Klucz jest niszczone przy terminacji workloadu. Dane persystentne (dokumenty, konfiguracja operatora) muszą być przechowywane w dedykowanym volume, również szyfrowanym.

REQ-WKL-008 — Workload musi eksponować health check endpoint odpytujący przez session broker. Brak odpowiedzi przez > 30 sekund skutkuje automatycznym restartem workloadu.

18.8 Wymagania dla Matrix

Status: [N] Normatywny Odbiorca: Architekt | Dev | Compliance | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 6.4, 17.2, 20.3

Matrix stanowi rdzeń komunikacyjny platformy SYLION, zapewniając szyfrowaną komunikację tekstową, przesyłanie plików oraz integrację z innymi workloadami. Deployment Matrix musi spełniać wymagania izolacji i minimalizacji metadanych.

REQ-MTX-001 — SYLION musi wdrażać własny homeserver Matrix (Synapse lub Dendrite) na infrastrukturze kontrolowanej. Korzystanie z publicznych homeserverów (matrix.org, element.io) jest zabronione dla ruchu produkcyjnego.

REQ-MTX-002 — Federacja musi być ograniczona wyłącznie do zatwierdzonych homeserverów. Lista zatwierdzonych serwerów jest definiowana w polityce tenanta. Domyślnie: brak federacji (izolowany homeserver). Federacja z innymi tenantami SYLION wymaga dwustronnej akceptacji.

REQ-MTX-003 — End-to-End Encryption (E2EE) jest obowiązkowe dla wszystkich pokoi (rooms) — zarówno grupowych, jak i 1:1. Pokoje bez E2EE nie mogą być tworzone w środowisku produkcyjnym. Szyfrowanie opiera się na protokole Olm/Megolm z kluczami zarządzanymi po stronie klienta.

REQ-MTX-004 — Minimalizacja metadanych: retencja membership history (kto był w pokoju) musi być ograniczona do okresu operacyjnego (np. 90 dni po opuszczeniu pokoju). Timestamp precision w logach federacyjnych musi być ograniczona do minut (nie sekund) gdzie to technicznie możliwe. Server-side metadata musi być minimalne.

REQ-MTX-005 — Weryfikacja kluczy klient-klient (cross-signing) musi być obowiązkowa dla STATE/SOVEREIGN. Operatorzy muszą zweryfikować tożsamości kryptograficzne swoich rozmówców. Dla STANDARD/PRO — silnie rekomendowane.

REQ-MTX-006 — Numer telefonu nie może być używany jako główny identyfikator tożsamości w Matrix. Identyfikatorem musi być Matrix ID powiązany z tożsamością organizacyjną (np. @operator:tenant.sylon.internal). Lookup by phone number jest wyłączony.

REQ-MTX-007 — Audit log musi rejestrować: tworzenie pokoju (kto, kiedy, typ, uczestnicy), zmiany członkostwa (join/leave/invite/ban), usunięcie wiadomości (kto, kiedy — bez treści), zmiany ustawień pokoju. Treść wiadomości nie jest logowana (E2EE uniemożliwia server-side logging treści).

REQ-MTX-008 — Backup kluczy E2EE: klucze sesji Megolm mogą być backupowane wyłącznie do serwera key backup z szyfrowaniem kluczem operatora (SSSS — Secure Secret Storage and Sharing). Key backup na zewnętrzne serwisy jest zabroniony.

18.9 Wymagania dla Signal compatibility workload

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 6.5, 17.3, 18.7, 18.10

Workload Signal (env-signal) stanowi komponent kompatybilności umożliwiający komunikację z kontaktami zewnętrznymi korzystającymi z Signal Messenger. Ze względu na zależność od infrastruktury zewnętrznej (Signal Foundation), workload ten podlega podwyższonym wymaganiom izolacji.

REQ-SIG-001 — env-signal musi działać wyłącznie w izolowanej microVM (Firecracker). Containerization bez hypervisor-level isolation jest niedopuszczalna, niezależnie od tieru. Izolacja microVM zapewnia, że ewentualna kompromitacja klienta Signal nie propaguje się na inne workloady.

REQ-SIG-002 — Egress z env-signal musi być ograniczony wyłącznie do infrastruktury Signal Foundation. Whitelist definiowany jest na poziomie ASN (Autonomous System Number) i zakresów IP publikowanych przez Signal. Ruch do jakichkolwiek innych celów jest blokowany i logowany jako anomalia.

REQ-SIG-003 — env-signal nie może mieć dostępu do schowka (clipboard) innych workloadów. Transfer tekstu lub plików z env-signal do env-matrix lub env-office wymaga jawnej akcji operatora i przejścia przez mechanizm CDR staging.

REQ-SIG-004 — Eksport plików z env-signal jest dopuszczalny wyłącznie poprzez CDR staging. Plik odebrany w Signal musi przejść pełny proces CDR (staging → analiza → rekonstrukcja → dostarczenie) przed udostępnieniem w innym workloadzie. Bezpośredni transfer plik → inny workload jest zablokowany.

REQ-SIG-005 — W interfejsie użytkownika env-signal musi być wyraźnie oznaczony jako workload zależny od zewnętrznej infrastruktury (external-dependency workload). Oznaczenie musi obejmować: wizualny indyktor (np. ramka w kolorze ostrzegawczym), tooltip informujący o ograniczeniach bezpieczeństwa, disclaimer przy pierwszym użyciu.

REQ-SIG-006 — env-signal musi być automatycznie odbudowywany (rebuild from clean image) przy każdej wykrytej anomalii: nietypowy ruch sieciowy, nieautoryzowany syscall, próba komunikacji z adresem spoza whitelist, crash klienta. Odbudowa: < 60 sekund.

REQ-SIG-007 — Rejestracja numeru Signal musi odbywać się w kontrolowany sposób: numer przypisany do operatora jest zarządzany przez management plane, operator nie może samodzielnie zmienić numeru ani zarejestrować nowego. Deprovisioning operatora obejmuje deaktywację numeru Signal.

REQ-SIG-008 — Logi env-signal muszą zawierać: start/stop workloadu, zdarzenia sieciowe (connect/disconnect do Signal infrastructure), zdarzenia CDR (plik odebrany, plik przetworzony). Treść wiadomości nie jest logowana (szyfrowanie Signal Protocol end-to-end).

18.10 Wymagania dla transferu plików i CDR

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 7.1, 17.2, 18.4, 18.9, 23.6

Content Disarm and Reconstruct (CDR) stanowi obowiązkowy mechanizm sanitizacji plików w architekturze SYLION. Każdy plik wchodzący do Zone 3 (środowisko operatora) musi przejść przez CDR.

REQ-CDR-001 — Staging jest obowiązkowy: plik odebrany przez dowolny workload (Matrix, Signal, przeglądarka, API) musi zostać umieszczony w strefie staging (bufor Zone 2/3 boundary) przed dostarczeniem do workloadu docelowego. Bezpośredni transfer file → workload jest zablokowany architektonicznie.

REQ-CDR-002 — Obsługiwane typy plików podlegające przetworzeniu CDR: PDF (wszystkie wersje do 2.0), dokumenty Office (OOXML: .docx, .xlsx, .pptx; ODF: .odt, .ods, .odp), obrazy (JPEG, PNG, TIFF, BMP, WebP), archiwa (ZIP — rekurencyjnie, z limitem głębokości zagnieżdżenia 3 poziomy), HTML/MHTML. Typy nieobsługiwane przez CDR muszą być automatycznie poddane kwarantannie z powiadomieniem operatora i admina.

REQ-CDR-003 — Przetwarzanie CDR musi odbywać się w efemerycznej microVM (Firecracker), która jest niszczona natychmiast po przetworzeniu pliku. MicroVM nie współdzieli filesystem, sieci ani pamięci z innymi procesami CDR ani workloadami. Każdy plik = nowa microVM.

REQ-CDR-004 — Metadane pliku muszą być usuwane (stripped) przed dostarczeniem do workloadu: EXIF (obrazy), właściwości dokumentu (autor, organizacja, ścieżki systemowe, komentarze, historia rewizji), osadzone obiekty zewnętrzne (OLE, makra — usuwane lub neutralizowane). Plik dostarczany operatorowi musi być „czysty” pod kątem metadanych.

REQ-CDR-005 — Przetworzony plik musi być dostarczony wyłącznie do workloadu, który go zażądał. Plik nie jest dostępny globalnie w środowisku operatora — trafia do dedykowanego katalogu workloadu z odpowiednimi uprawnieniami.

REQ-CDR-006 — Pełny audit trail transferu musi zawierać: hash pliku oryginalnego (SHA-256), hash pliku po CDR, operator ID, workload źródłowy, workload docelowy, timestamp, rozmiar pliku, typ MIME (wykryty, nie zadeklarowany), decyzja CDR (accept/reject/quarantine), czas przetwarzania. Audit trail przechowywany w Zone 4.

REQ-CDR-007 — Limity: maksymalny rozmiar pliku 100 MB (konfigurowalny per tenant), maksymalny czas przetwarzania 120 sekund (timeout → quarantine), maksymalna głębokość archiwum 3 poziomy.

REQ-CDR-008 — Pliki poddane kwarantannie muszą być przechowywane w zaszyfrowanym storage Zone 2 z retencją konfigurowalną (domyślnie 30 dni). Dostęp do kwarantanny: wyłącznie SOC/admin z uprawnieniem forensics.

18.11 Wymagania dla IAM i polityk

Status: [N] Normatywny Odbiorca: Architekt | Dev | Compliance | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 9.1, 17.3, 17.5, 18.5, 23.3

System zarządzania tożsamościami i politykami (IAM) stanowi fundament modelu Zero Trust w SYLION, odpowiadając za uwierzytelnianie, autoryzację i cykl życia tożsamości operatorów.

REQ-IAM-001 — Każdy operator musi posiadać unikalną tożsamość cyfrową w systemie. Współdzielenie kont jest zabronione. Tożsamość musi być powiązana z konkretną osobą fizyczną, potwierdzoną w procesie identity proofing przy onboardingu.

REQ-IAM-002 — MFA jest obowiązkowe dla wszystkich operatorów. Wymagane mechanizmy: FIDO2/WebAuthn z kluczem sprzętowym — obowiązkowy dla STATE/SOVEREIGN; TOTP (Time-based One-Time Password) — minimum dla STANDARD/PRO. SMS OTP jest zabronione jako metoda MFA.

REQ-IAM-003 — Autoryzacja musi opierać się na modelu RBAC+ABAC (Role-Based + Attribute-Based Access Control). Role definiują bazowy zestaw uprawnień; atrybuty (lokalizacja, czas, device posture, risk score) modyfikują dostęp kontekstowo. Polityki muszą być wyrażone w formalnym języku (np. OPA/Rego, Cedar) i wersjonowane w Git.

REQ-IAM-004 — Just-In-Time (JIT) access jest obowiązkowy dla operacji uprzywilejowanych: zmiana polityki, dostęp do management plane, operacje na kluczach. Uprawnienie JIT jest przyznawane na określony czas (TTL), z wymogiem uzasadnienia (justification) i zatwierdzenia (approval) przez drugiego administratora.

REQ-IAM-005 — Recertyfikacja dostępu musi odbywać się minimum raz na kwartał. Manager/administrator tenanta przegląda aktywne uprawnienia operatorów i potwierdza lub odwołuje. Nierecertyfikowane uprawnienia są automatycznie zawieszane po 7 dniach od terminu.

REQ-IAM-006 — Rewokacja przy offboardingu musi nastąpić w czasie < 5 minut: dezaktywacja tożsamości → unieważnienie tokenu MFA → rewokacja certyfikatu VPN → terminacja aktywnych sesji → zablokowanie dostępu do wszystkich workloadów. Proces musi być jednoetapowy (single admin action triggers all revocations).

REQ-IAM-007 — Federacja SSO musi wspierać OIDC i SAML 2.0 z konfigurowanym mapowaniem atrybutów (claim mapping). Platforma musi obsługiwać minimum: Azure AD, Okta, Keycloak, Google Workspace. Dodatkowi IdP konfigurowalni przez API.

REQ-IAM-008 — Sealed recovery key musi być generowany przy onboarding operatora, zaszyfrowany kluczem publicznym admina/HSM i przechowywany w bezpiecznym storage. Recovery key umożliwia emergency re-enrollment w przypadku utraty FIDO2 key. Użycie recovery key wymaga dual authorization i jest logowane jako P1 event.

Harmonogram recertyfikacji FIDO2 per tier: Tier STATE/SOVEREIGN — obowiązkowa recertyfikacja co 30 dni (wymaganie operacyjne sektora obronnego); Tier PRO — recertyfikacja co 90 dni; Tier STANDARD — recertyfikacja co 180 dni. Recertyfikacja = ponowne potwierdzenie aktywnego klucza FIDO2 w procedurze dual-authorization. Operator który nie przeszedł recertyfikacji w terminie traci dostęp do sesji do czasu weryfikacji.

18.12 Wymagania dla HSM/PKI/PQC

Status: [N] Normatywny Odbiorca: Architekt | Infra | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 7.3, 17.3, 19.3

HSM (Hardware Security Module) i PKI (Public Key Infrastructure) stanowią rdzeń zaufania kryptograficznego platformy SYLION. PQC (Post-Quantum Cryptography) rozszerza ten rdzeń o odporność na zagrożenia kwantowe.

REQ-HSM-001 — Minimalne wymagania walidacyjne: FIPS 140-3 Level 3 dla tieru STATE/SOVEREIGN, FIPS 140-3 Level 2 dla STANDARD/PRO. Dla wdrożeń sovereign dopuszczalny jest również eIDAS-qualified HSM. HSM bez walidacji FIPS lub eIDAS nie może być używany w produkcji.

REQ-HSM-002 — Wszystkie operacje Root CA (generowanie klucza root, podpisywanie certyfikatów intermediate CA) muszą odbywać się wewnątrz HSM. Klucz prywatny Root CA nigdy nie opuszcza HSM — nawet w formie zaszyfrowanej.

REQ-HSM-003 — Ceremonia kluczy (key ceremony) musi być udokumentowana z dual control: minimum dwóch autoryzowanych oficerów kryptograficznych musi uczestniczyć w generowaniu klucza root i podpisywaniu intermediate CA. Ceremonia musi być nagrywana (video) i archiwizowana jako evidence audytowe.

REQ-HSM-004 — Eksport kluczy prywatnych Root CA i Intermediate CA jest zabroniony. Klucze operacyjne (workload keys, session keys) mogą być eksportowane wyłącznie w formie wrapped (zaszyfrowanej kluczem HSM) na potrzeby dystrybucji do komponentów runtime. Unwrapping następuje w pamięci komponentu, klucz nie jest zapisywany na dysku.

REQ-HSM-005 — PQC readiness: platforma musi wspierać algorytmy post-quantowe ML-KEM (Kyber) dla wymiany kluczy i ML-DSA (Dilithium) dla podpisów cyfrowych w tierze STATE/SOVEREIGN. Wdrożenie w trybie hybrydowym: klasyczny (ECDSA P-384 + ECDH P-384) + PQC (ML-DSA-65 + ML-KEM-768) jako dual stack, zapewniający bezpieczeństwo zarówno wobec zagrożeń klasycznych, jak i kwantowych.

REQ-HSM-006 — Dla wdrożeń sovereign musi istnieć opcja on-premise HSM: fizyczne urządzenie HSM zlokalizowane w datacenter klienta, zarządzane przez personel klienta. SYLION dostarcza integrację (PKCS#11, KMIP) i dokumentację, ale nie ma dostępu do kluczy klienta.

REQ-HSM-007 — Rotacja kluczy: certyfikaty intermediate CA — rotacja co 2 lata; certyfikaty workload — rotacja co 90 dni (automatyczna); klucze sesji — efemeryczne (per-session, niszczone po zakończeniu sesji). Root CA — ważność 10 lat z planowaną rotacją co 7 lat.

REQ-HSM-008 — CRL (Certificate Revocation List) i OCSP muszą być obsługiwane. Rewokacja certyfikatu musi być propagowana do wszystkich komponentów w czasie < 5 minut (CRL push + OCSP stapling).

18.13 Wymagania dla management plane

Status: [N] Normatywny Odbiorca: Architekt | Infra | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.1, 17.3, 17.4, 23.3

Management plane (Zone 5) stanowi najwyższą strefę zaufania w architekturze SYLION, odpowiadając za konfigurację, provisioning i zarządzanie całą platformą.

REQ-MGT-001 — Management plane musi być fizycznie lub logicznie oddzielony od operator plane (Zone 0–3). Separacja sieciowa: brak routingu między Zone 5 a Zone 0/Zone 3. Dostęp do Zone 5 wyłącznie przez dedykowaną ścieżkę (bastion host w Zone 4/5 boundary).

REQ-MGT-002 — Dostęp do management plane wymaga przejścia przez bastion host z: uwierzytelnieniem wielokrotnym (hardware MFA — FIDO2 lub smartcard), logowaniem sesji (session recording), ograniczeniem czasowym (session TTL ≤ 4 godziny), allowlistą source IP.

REQ-MGT-003 — Operacje destrukcyjne (usunięcie operatora, zmiana polityki bezpieczeństwa, rotacja klucza CA, modyfikacja konfiguracji G1/G2) wymagają dual authorization: inicjacja przez jednego administratora + zatwierdzenie przez drugiego. Zatwierdzenie musi nastąpić w osobnej sesji uwierzytelniania.

REQ-MGT-004 — Wszystkie operacje management plane muszą być logowane do Zone 4 z: identyfikatorem administratora, opisem operacji, parametrami (before/after dla zmian konfiguracji), timestamp, wynikiem, łańcuchem zatwierdzenia (kto zatwierdził, kiedy).

REQ-MGT-005 — Freeze capability (tryb zamrożenia): management plane musi wspierać tryb freeze, w którym wszelkie zmiany konfiguracyjne są zablokowane. Freeze jest aktywowany: ręcznie (przez uprawnionego admina), automatycznie (przy wykryciu incydentu P1), lub harmonogramowo (np. na czas audytu). Unfreeze wymaga dual authorization i jest logowane jako P1 event.

REQ-MGT-006 — Konfiguracja musi być zarządzana wyłącznie przez IaC (Terraform + Ansible). Ręczna modyfikacja konfiguracji (manual config drift) musi być wykrywana automatycznie (drift detection) i sygnalizowana jako incydent bezpieczeństwa. Procedura remediacji: rollback do stanu IaC.

REQ-MGT-007 — Procedura break-glass (dostęp awaryjny) musi być udokumentowana, przetestowana kwartalnie i dostępna offline (wydruk w sejfie fizycznym). Break-glass umożliwia dostęp do management plane w przypadku awarii systemu IAM, z wykorzystaniem sealed credentials przechowywanych w HSM lub fizycznym sejfie. Każde użycie break-glass generuje alerty P1 i wymaga post-incident review.

REQ-MGT-008 — Management plane musi wspierać role-based access: Platform Admin (pełny dostęp), Tenant Admin (dostęp ograniczony do swojego tenanta), Security Admin (polityki i audyt), Infra Admin (infrastruktura bez dostępu do polityk). Żadna rola nie ma domyślnie pełnego dostępu — zasada least privilege.

18.14 Wymagania dla monitoringu, SIEM i IR

Status: [N] Normatywny Odbiorca: SOC | Infra | Architekt | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 14.1, 17.4, 17.7, 23.7

Monitoring, SIEM i Incident Response (IR) stanowią triadę operacyjną zapewniającą wykrywalność, analizę i reagowanie na incydenty bezpieczeństwa.

REQ-MON-001 — Wszystkie zdarzenia bezpieczeństwa muszą dotrzeć do systemu SIEM w czasie < 60 sekund od momentu wystąpienia. Łańcuch: komponent generujący → agent (Fluent Bit/OpenTelemetry Collector) → agregator (Zone 4) → SIEM. Opóźnienie łańcucha musi być monitorowane — przekroczenie 60s generuje alert operacyjny.

REQ-MON-002 — Storage logów musi być WORM (Write Once Read Many) z minimalną retencją 2 lata. Implementacja WORM: object lock na storage (np. S3 Object Lock, Azure Immutable Blob) lub dedykowane rozwiązanie WORM (NetApp SnapLock, Wasabi Object Lock). Logi nie mogą być modyfikowane ani usuwane przed upływem retencji — nawet przez Platform Admin.

REQ-MON-003 — Integralność logów musi być zapewniona przez hash chains: każdy blok logów (np. 1000 rekordów) jest hashowany, a hash jest włączany do następnego bloku. Łańcuch hashów umożliwia wykrycie manipulacji lub usunięcia rekordów. Weryfikacja integralności musi być automatyczna (scheduled job co 1h) i on-demand (dla forensics).

REQ-MON-004 — Separacja logów: logi widoczne dla tenant admin (aktywność operatorów tenanta, zdarzenia sesji, CDR decisions) vs logi wewnętrzne SYLION (infrastruktura, management plane, inter-component communication). Tenant admin nie widzi logów innych tenantów ani logów platformowych. SYLION operator nie widzi treści komunikacji tenantów.

REQ-MON-005 — Klasyfikacja severity incydentów: P1 (Critical — kompromitacja tenanta, breach, utrata danych) — response < 15 minut; P2 (High — degradacja usługi, anomalia bezpieczeństwa) — response < 1 godzina; P3 (Medium — pojedynczy alert, performance degradation) — response < 4 godziny; P4 (Low — informacyjny) — response next business day.

REQ-MON-006 — P1 alert response: SOC musi podjąć pierwszą akcję diagnostyczną w ciągu 15 minut od alertu. Eskalacja do Security Lead w ciągu 30 minut. Powiadomienie klienta (tenant admin) w ciągu 1 godziny dla incydentów wpływających na jego operatorów.

REQ-MON-007 — Automated containment: dla znanych wzorców ataków (brute force MFA, anomalny egress, lateral movement attempt) system musi automatycznie: zablokować source (IP/operator), izolować workload, wygenerować alert P1, zachować evidence (snapshot stanu). Human-in-the-loop wymagany dla: terminacji tenanta, rewokacji CA, freeze management plane.

18.15 Wymagania dla backup, DR i ciągłości działania

Status: [N] Normatywny Odbiorca: Infra | Architekt | Zarząd | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 8.3, 17.4, 21.1, 23.8

Strategia backup i DR w SYLION musi uwzględniać specyfikę architektury: workloady są efemeryczne, dane treściowe chronione E2EE, a klucze kryptograficzne celowo nie podlegają tradycyjnemu backupowi.

REQ-BCK-001 — Backup konfiguracji musi być szyfrowany (AES-256-GCM, klucz z HSM) i niemodyfikowalny (immutable storage). Zakres: konfiguracja Terraform state, polityki IAM/Policy Engine, konfiguracja G1/G2, konfiguracja DNS, certyfikaty (publiczne — prywatne w HSM), konfiguracja monitoringu. Backup wykonywany minimum co 4 godziny (incremental) i co 24 godziny (full).

REQ-BCK-002 — Klucze kryptograficzne workloadów nie podlegają backupowi (keys never backed up). Workloady są efemeryczne — w przypadku utraty, workload jest odbudowywany z czystego obrazu z nowymi kluczami generowanymi z HSM. Klucze Root CA i Intermediate CA są chronione wyłącznie w HSM (z replikacją HSM-to-HSM dla HA, nie przez backup tradycyjny).

REQ-BCK-003 — RPO: < 24 godzin dla konfiguracji (w praktyce < 4h dzięki incremental backup). Dla danych operatora (dokumenty w env-office, dane CRM) — zależne od konfiguracji tenanta, z domyślnym RPO < 1h (continuous backup z encrypted volume snapshots).

REQ-BCK-004 — RTO: < 4 godziny dla STANDARD (obejmuje: restore konfiguracji, provisioning infrastruktury, deployment workloadów, weryfikacja); < 1 godziny dla STATE/SOVEREIGN (wymaga hot standby w regionie DR z pre-provisioned infrastrukturą).

REQ-BCK-005 — DR musi być testowane minimum raz na kwartał. Test musi obejmować: pełny failover do regionu DR, weryfikację dostępności sesji operatorów, weryfikację integralności konfiguracji, pomiar faktycznego RTO, test procedury failback. Wyniki dokumentowane jako evidence audytowe.

REQ-BCK-006 — Storage backupu musi znajdować się w odrębnej strefie/regionie niż primary. Dla STATE/SOVEREIGN: backup w innym datacenter (minimum 100 km separacji fizycznej). Backup nie może być dostępny z Zone 0–3 (separacja sieciowa).

REQ-BCK-007 — Weryfikacja restore: każdy backup musi być weryfikowany (restore verification) — minimum raz na tydzień automatyczny test restore do środowiska staging z walidacją integralności. Evidence: raport z datą, wynikiem, czasem restore.

Rozdział 19. Priorytetyzacja backlogu i kryteria MVP

19.1 Co wchodzi do MVP

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Dev | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.1, 17.2, 18.1–18.15

Minimum Viable Product (MVP) platformy SYLION definiuje najmniejszy zestaw komponentów i funkcji, który spełnia fundamentalną obietnicę produktową: bezpieczna komunikacja i praca zdalna w modelu Thin Client z izolacją kryptograficzną i Zero Trust. MVP nie jest prototypem — jest produkcyjnym systemem minimalnym, na którym można oprzeć pierwsze wdrożenie komercyjne z ograniczonym zestawem klientów (early adopters).

Zakres MVP obejmuje następujące komponenty w pełnej gotowości produkcyjnej:

Infrastruktura rdzeniowa: G1 (terminacja IPsec, stateful inspection L3/L4, HA active-passive, rate limiting, anti-DDoS) + G2 (Policy Engine, device posture evaluation, session routing, CDR trigger, HA active-active). Oba gateways muszą spełniać wymagania z rozdziałów 18.4 i 18.5 — z wyjątkiem Confidential Computing, który nie jest wymagany w MVP.

Transport: IPsec IKEv2 (strongSwan z modułem FIPS) z pełnym profilem kryptograficznym (AES-256-GCM, SHA-384, P-384, PFS). NAT-T obsługiwany. MOBIKE opcjonalny w MVP.

Terminal: Pixel z GrapheneOS jako jedyny wspierany terminal mobilny w MVP. Laptop (hardened Linux) jako opcja desktop. Klient SYLION: tunel IPsec, FIDO2 auth UI, pixel streaming, audio.

IAM: OIDC federation (minimum jeden IdP: Keycloak wewnętrzny) + FIDO2 MFA. RBAC z minimum 3 rolami (operator, admin, SOC). SAML 2.0 — nie wymagany w MVP (wchodzi w 1.x).

Workloady: Jedno środowisko operatora z dwoma workloadami: env-matrix (komunikacja E2EE — Synapse homeserver, klient Element) i env-browser (przeglądarka z egress proxy, URL filtering). Rootless containers z seccomp/AppArmor jako runtime.

CDR: Obsługa PDF i dokumentów Office (OOXML). Przetwarzanie w efemerycznej microVM. Audit trail pełny. Kwarantanna dla nieobsługiwanych typów.

Observability: Zone 4 logging (strukturyzowane, WORM, hash chain), metryki (Prometheus), alerty (Alertmanager). Eksport do SIEM — CEF minimum.

Management plane: Bastion host, IaC (Terraform + Ansible), Vault dla secrets, dual authorization dla operacji destrukcyjnych.

Poza zakresem MVP: Confidential Computing (SEV-SNP), PQC, sovereign deployment, env-signal, env-voice, env-crm, env-office (pełny — uproszczona wersja może wejść), BYOK, multi-region HA, partner API, audit API, advanced forensics, session recording.

19.2 Co wchodzi do wersji produkcyjnej 1.x

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Dev | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 17.2, 17.5, 18.6–18.11

Wersja 1.x stanowi pełną realizację tieru PRO i rozszerzenie STANDARD o wszystkie planowane workloady. Przejście z MVP do 1.x jest napędzane przez potrzeby pierwszych klientów komercyjnych i ich wymagania dotyczące pełnego zestawu narzędzi pracy.

Rozszerzenie workloadów: Pełny zestaw typów workloadowych: env-office (LibreOffice Online z pełną obsługą OOXML i ODF, wersjonowanie dokumentów, współdzielenie w ramach tenanta), env-crm (konteneryzowana aplikacja CRM z API integration, dostęp do danych klienta, generowanie raportów), env-voice (komunikacja głosowa z szyfrowanym transportem, codec Opus, integracja z Matrix voice rooms). Wszystkie workloady w modelu rootless container z profilem seccomp/AppArmor. MicroVM (Firecracker) dostępna jako opcja dla workloadów podwyższonego ryzyka.

CDR pełny zakres: Rozszerzenie CDR o wszystkie obsługiwane typy plików: obrazy (JPEG, PNG, TIFF, BMP, WebP), archiwa (ZIP rekurencyjnie), HTML/MHTML. Kwarantanna z interfejsem SOC do przeglądu.

Hardware attestation: Pełna integracja Android Key Attestation z G2 device posture evaluation. Terminal, który nie przejdzie attestation, otrzymuje obniżony score i ograniczony dostęp.

FIDO2 pełna integracja: Obsługa wielu kluczy FIDO2 per operator (primary + backup), self-service enrollment nowego klucza (z zatwierdzeniem admin), recovery flow z sealed recovery key.

Multi-region HA: Deployment w minimum dwóch regionach z automatycznym failover. Data residency enforcement per tenant. Load balancing G1 z GeoDNS.

BYOK (Bring Your Own Key): Klient może dostarczyć własne klucze szyfrowania (wrapped, importowane do HSM SYLION) dla danych swojego tenanta. BYOK dostępny dla PRO i wyżej.

Audit API: RESTful API umożliwiający tenant admin programowy dostęp do logów audytowych swojego tenanta. Filtrowanie, paginacja, eksport. OAuth 2.0 + mTLS.

Partner API: API umożliwiający partnerom/integratorom automatyzację provisioning, konfiguracji i monitorowania wdrożeń klienckich. Rate limiting, per-partner credentials, audit log.

SSO rozszerzony: SAML 2.0 federation, multi-IdP per tenant, attribute mapping UI.

19.3 Co wchodzi do 2.x

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Compliance | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 18.12, 19.4

Wersja 2.x buduje fundament tieru STATE, wprowadzając technologie wymagane przez klientów z sektora publicznego, militarnego i regulowanego. Kluczowe filary 2.x to Confidential Computing, kryptografia post-quantowa i suwerenność infrastrukturalna.

Confidential Computing dla Zone 3: Workloady operatorów w tierze STATE działają wewnątrz Trusted Execution Environments: AMD SEV-SNP (Secure Encrypted Virtualization — Secure Nested Paging) dla microVM Firecracker, lub Intel TDX (Trust Domain Extensions) jako alternatywa. Confidential Computing zapewnia, że dane w pamięci operacyjnej workloadu są szyfrowane i niedostępne dla operatora infrastruktury (SYLION ani dostawca IaaS). Attestation: remote attestation microVM musi być weryfikowalny przez G2 przed przyznaniem sesji.

PQC hybrid transport: IPsec IKEv2 z hybrydową wymianą kluczy: klasyczny ECDH P-384 + ML-KEM-768 (Kyber). Podpisy: ECDSA P-384 + ML-DSA-65 (Dilithium). Tryb hybrydowy zapewnia bezpieczeństwo retroaktywne (harvest-now-decrypt-later protection) — nawet jeśli algorytm klasyczny zostanie złamany przez komputer kwantowy, warstwa PQC chroni poufność. Implementacja: strongSwan z PQC plugin (liboqs) lub dedykowany moduł.

On-prem HSM support: Pełna integracja z HSM fizycznymi lokalizowanymi w datacenter klienta. Interfejsy: PKCS#11, KMIP. Obsługiwane modele: Thales Luna, Entrust nShield, Utimaco. Dokumentacja key ceremony specyficzna dla każdego modelu. Klient zarządza HSM samodzielnie — SYLION nie ma dostępu do kluczy.

Sovereign deployment option: Pełna ścieżka wdrożeniowa na infrastrukturze klienta bez zależności runtime od chmury publicznej. Package: obrazy VM/container, IaC (Terraform + Ansible), dokumentacja, playbooks operacyjne. Aktualizacje dostarczane jako podpisane pakiety offline (USB/secured transfer), nie przez pull z repozytorium chmurowego.

Zaawansowany monitoring: ML-based anomaly detection na telemetrii (baseline per operator/tenant, alert na odchylenia), advanced correlation rules w SIEM, automated threat intelligence feed integration (STIX/TAXII), enriched incident context (geolokalizacja, reputation score source IP).

Enhanced forensics: Capability do pełnej rekonstrukcji timeline incydentu z danych Zone 4: kto, kiedy, co, skąd, z jakiego urządzenia, z jakim wynikiem — z granularnością do pojedynczej decyzji Policy Engine. Export forensic package (chain of custody maintained) w formacie kompatybilnym z narzędziami DFIR.

19.4 Co wchodzi do 3.x

Status: [E] Eksperymentalny → [R] Rekomendowany (po walidacji) Odbiorca: Zarząd | Architekt | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 18.12, 19.3

Wersja 3.x realizuje pełną wizję tieru STATE/SOVEREIGN z mechanizmami certyfikacyjnymi i zdolnościami operacyjnymi wymaganymi przez organizację o najwyższych wymaganiach bezpieczeństwa — agendy rządowe, służby specjalne, infrastruktura krytyczna.

Full PQC PKI: Pełna infrastruktura klucza publicznego oparta na algorytmach post-quantowych. Root CA z kluczem ML-DSA-87 (Dilithium Level 5) w HSM z wsparciem PQC. Intermediate CA: ML-DSA-65. Certyfikaty workload: ML-DSA-44 + ML-KEM-512 (hybrydowe z klasycznymi ECDSA/ECDH w okresie przejściowym). CRL i OCSP z podpisami PQC. Pełna ścieżka certyfikacji PQC-native bez zależności od algorytmów klasycznych.

Air-gap deployment mode: Tryb wdrożeniowy dla środowisk fizycznie odizolowanych od Internetu. Wszystkie aktualizacje (OS, aplikacje, polityki, sygnatury) dostarczane przez nośniki fizyczne z weryfikacją integralności (podpis cyfrowy, hash manifest). Brak telemetrii wychodzącej. DNS wewnętrzny. NTP wewnętrzny (stratum 1 z GPS/cesium). Monitoring zamknięty — SIEM on-premise.

Common Criteria evaluation path: Przygotowanie platformy do certyfikacji Common Criteria (CC) EAL4+. Obejmuje: Security Target (ST), Functional Specification, TOE Design, Implementation Representation, Vulnerability Analysis. Wydzielenie TOE (Target of Evaluation) obejmującego: G1, G2, Policy Engine, session broker, CDR, IAM, HSM integration. Współpraca z akredytowanym laboratorium.

FedRAMP audit package: Pakiet dokumentacji i evidence umożliwiający klientom przejście audytu FedRAMP (dla rynku US) lub odpowiedników europejskich (C5 w Niemczech, SecNumCloud we Francji, krajowe schematy). Obejmuje: System Security Plan (SSP), Plan of Action and Milestones (POA&M), Continuous Monitoring plan, Incident Response plan, automated evidence collection.

Federated homeserver: Matrix homeserver z kontrolowaną federacją między tenantami i organizacjami — umożliwiający bezpieczną komunikację międzyorganizacyjną z zachowaniem E2EE, izolacji metadanych i audytowalności. Federacja wyłącznie z homeserverami spełniającymi zdefiniowane kryteria bezpieczeństwa (mutual attestation).

Blind Broker dla voice/video: Jeśli RFC i implementacja dojrzeją — broker głosu/video, który nie ma dostępu do treści strumienia (forward-only, zero-knowledge routing). Eksperymentalny w 3.0, produkcyjny w 3.x jeśli walidacja potwierdzi bezpieczeństwo.

Micro-watermarking: Niewidoczny watermark w strumieniu pikselowym umożliwiający identyfikację źródła wycieku (leak tracing). Watermark zawiera: operator ID (zahashowany), timestamp, session ID. Walidacja: odporność na kompresję, screenshot, fotografia ekranu. Eksperymentalny — wymaga walidacji pod kątem false positives i privacy implications.

19.5 Blokery produkcyjne (production blockers)

Status: [N] Normatywny Odbiorca: Zarząd | Dev | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.9, 19.1

Blokery produkcyjne definiują warunki konieczne (gates), które muszą być spełnione przed jakimkolwiek wdrożeniem produkcyjnym — zarówno MVP, jak i każdym kolejnym release. Niespełnienie choćby jednego blokera wstrzymuje release.

GATE-PROD-001 — Penetration test: Niezależny test penetracyjny przeprowadzony w ciągu ostatnich 90 dni, obejmujący external perimeter, tenant isolation, privilege escalation. Wszystkie findings Critical i High muszą być zamknięte (remediated). Findings Medium — zamknięte lub z udokumentowanym planem remediacji i kompensacją.

GATE-PROD-002 — Automated regression: 100% pass rate na testach: unit, integration, E2E, security (SAST, DAST, dependency scan). Zero known Critical/High security findings z automated scanning.

GATE-PROD-003 — DR test: Ćwiczenie DR przeprowadzone w ciągu ostatnich 90 dni z udokumentowanym wynikiem potwierdzającym spełnienie RTO/RPO.

GATE-PROD-004 — Audit trail verification: Weryfikacja, że wszystkie wymagane zdarzenia audytowe są generowane, dostarczane do Zone 4 w < 60s, i niemodyfikowalne. Test: symulacja operacji → weryfikacja rekordu w Zone 4.

GATE-PROD-005 — IAM full lifecycle: Weryfikacja pełnego cyklu: provisioning → sesja → rewokacja → weryfikacja braku dostępu. Czas rewokacji < 5 minut.

GATE-PROD-006 — CDR effectiveness: Testy CDR z zestawem próbek zawierających znane payloads (makra, embedded OLE, steganografia, polyglot files). CDR musi neutralizować 100% próbek z zestawu testowego.

GATE-PROD-007 — Immutability verification: Weryfikacja, że infrastruktura jest odtwarzalna z laC. Test: zniszczenie środowiska → rebuild z kodu → weryfikacja funkcjonalności. Czas rebuild ≤ 30 minut dla środowiska operatora.

19.6 Blokerzy rynków regulowanych

Status: [N] Normatywny Odbiorca: Compliance | Zarząd | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 17.8, 19.5, 23.8

Wdrożenia dla klientów z sektorów regulowanych (finansowy, ubezpieczeniowy, zdrowotny, energetyczny) wymagają spełnienia dodatkowych wymagań ponad bazowe blokerzy produkcyjne. Blokerzy te muszą być spełnione przed wdrożeniem w danym sektorze.

GATE-REG-001 — Data residency enforcement: Techniczna weryfikacja, że dane tenanta nie opuszczają skonfigurowanego regionu. Test: monitoring ruchu sieciowego, audyt storage locations, weryfikacja backup locations. Raport z evidence.

GATE-REG-002 — Retention compliance: Konfiguracja retencji logów zgodna z wymaganiami regulatora: minimum 5 lat dla sektora finansowego (MiFID II), minimum 10 lat dla dokumentacji medycznej (HIPAA/lokalne regulacje), konfigurowalne per tenant.

GATE-REG-003 — Right to erasure process: Udokumentowany i przetestowany proces realizacji Art. 17 GDPR: żądanie → weryfikacja → identyfikacja danych → usunięcie → evidence → raport. Czas realizacji ≤ 30 dni. Testowany minimum raz na kwartał.

GATE-REG-004 — Incident notification: Procedura powiadamiania klientów regulowanych o incydentach bezpieczeństwa: ≤ 24 godziny dla sektora finansowego (DORA), ≤ 72 godziny dla GDPR (Art. 33). Procedura przetestowana i udokumentowana.

GATE-REG-005 — Third-party audit readiness: Platforma musi być gotowa na audyt zewnętrzny (SOC 2 Type II, ISO 27001, lub równoważny) w zakresie: kontrole bezpieczeństwa, zarządzanie zmianami, incident response, ciągłość działania. Evidence zbierany automatycznie.

19.7 Blokerzy poziomu sovereign/state

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 18.12, 19.3, 19.4

Tier STATE/SOVEREIGN wymaga spełnienia najwyższych wymagań bezpieczeństwa, kryptografii i suwerenności, wykraczających poza standardowe blokerzy.

GATE-SOV-001 — Confidential Computing operational: AMD SEV-SNP lub Intel TDX w pełni operacyjne dla workloadów Zone 3. Remote attestation zintegrowane z G2. Weryfikacja: workload nie jest czytelny z poziomu hypervisora (memory dump test).

GATE-SOV-002 — PQC transport operational: IPsec IKEv2 z hybrydowym ML-KEM + ECDH operacyjny. Weryfikacja: key exchange z algorytmem PQC, regression test na kompatybilność z terminalami.

GATE-SOV-003 — On-prem HSM validated: Integracja z minimum jednym modelem HSM on-premise (Thales Luna lub Entrust nShield) przetestowana end-to-end: key ceremony, certificate signing, CRL, OCSP, key rotation.

GATE-SOV-004 — Common Criteria evaluation initiated: Security Target zatwierdzony, kontrakt z akredytowanym laboratorium podpisany, TOE wydzielony. Evaluation nie musi być ukończony na moment release 3.x, ale musi być w toku.

GATE-SOV-005 — No foreign dependency: Żaden komponent runtime w ścieżce krytycznej (G1, G2, Policy Engine, HSM, IAM, Zone 4 logging) nie może zależeć od usługi zarządzanej (managed service) dostawcy spoza jurysdykcji klienta. Weryfikacja: dependency mapping z klasyfikacją jurysdykcyjną.

GATE-SOV-006 — Air-gap capable: Platforma musi być zdolna do pełnej operacji bez łączności internetowej (po initial deployment). Weryfikacja: 72-godzinny test air-gap z pełną funkcjonalnością.

19.8 Backlog strategiczny

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 19.3, 19.4

Backlog strategiczny obejmuje inwestycje architektoniczne o horyzoncie 2–5 lat, które nie wchodzą do konkretnej wersji, ale kształtują kierunek ewolucji platformy. Każdy element backlogu strategicznego wymaga dedykowanego PoC (Proof of Concept) i business case przed włączeniem do roadmapy.

STRAT-001 — Multi-cloud abstraction layer: Warstwa abstrakcji umożliwiająca seamless provisioning i operację na wielu dostawcach IaaS (AWS, GCP, Azure, OVH, Hetzner) bez modyfikacji laC wyższego poziomu. Cel: live migration tenanta między dostawcami, multi-cloud HA (primary w AWS, DR w GCP). Wyzwanie: różnice w sieciach, TEE, storage API.

STRAT-002 — Edge compute nodes: Węzły obliczeniowe SYLION lokalizowane bliżej operatora (edge PoP), redukujące latencję pixel streaming. Model: G1 na edge, G2 + workloady w centralnej lokalizacji, lub pełny stack na edge dla sovereign. Wyzwanie: utrzymanie security posture na edge, physical security.

STRAT-003 — Hardware-defined perimeter: Dedykowane urządzenie sieciowe SYLION (appliance) łączące router dostępowy + hardened terminal w jednym sprzęcie. Cel: simplifykacja wdrożenia, redukcja surface area na stronie operatora. Wyzwanie: supply chain, physical security, koszt.

STRAT-004 — Federated identity mesh: Sieć wzajemnie zaufanych tożsamości między tenantami SYLION, umożliwiająca bezpieczną współpracę międzyorganizacyjną bez centralnego brokera tożsamości. Oparta na decentralized identifiers (DID) i verifiable credentials (VC). Wyzwanie: key management, revocation, trust establishment.

STRAT-005 — Confidential Computing for management plane: Rozszerzenie TEE na management plane (Zone 5), zapewniające, że nawet SYLION operator nie ma dostępu do plaintext konfiguracji tenanta. Ultimate zero-knowledge platform. Wyzwanie: operability, debugging, incident response w TEE.

19.9 Backlog eksperymentalny

Status: [E] Eksperymentalny Odbiorca: Architekt | Dev Wpływ na baseline: Niski (do momentu promocji) Powiązane rozdziały: 19.4, 19.10

Backlog eksperymentalny zawiera technologie i koncepcje, które mogą znacząco podnieść bezpieczeństwo lub użyteczność platformy, ale wymagają badań, PoC i walidacji przed włączeniem do roadmapy produkcyjnej. Każdy element eksperymentalny musi mieć zdefiniowane kryteria sukcesu (success criteria) i kryteria porzucenia (abandon criteria).

EXP-001 — Blind Broker dla desktop streaming: Rozszerzenie koncepcji Blind Broker (zero-knowledge routing) na strumień pikselowy. Broker nie widzi treści wyświetlanej operatorowi — jedynie routuje zaszyfrowany strumień. Wyzwanie: jak zapewnić jakość usługi (QoS) bez inspekcji strumienia, jak implementować session recording (jeśli wymagane) bez dostępu do treści. PoC: strumień szyfrowany E2E terminal ↔ workload z brokerem forwardującym.

EXP-002 — QKD (Quantum Key Distribution) experiments: Integracja z siecią QKD jako dodatkowa warstwa dystrybucji kluczy dla transportu IPsec. QKD zapewnia information-theoretic security — odporność niezależną od mocy obliczeniowej atakującego. Wyzwanie: dostępność infrastruktury QKD, zasięg geograficzny, koszt. Kryterium sukcesu: PoC z dostawcą QKD (ID Quantique, Toshiba) na dystansie > 50 km.

EXP-003 — Federated ML dla anomaly detection: Uczenie federacyjne (Federated Learning) modeli detekcji anomalii na teledziennych wielu tenantów bez ujawniania danych poszczególnych tenantów. Każdy tenant trenuje model lokalnie, agregacja odbywa się na serwerze SYLION (privacy-preserving aggregation). Cel: lepsza detekcja zagrożeń bez naruszania prywatności. Wyzwanie: data heterogeneity, model poisoning, privacy verification.

EXP-004 — Homomorphic encryption dla CDR metadata analysis: Analiza metadanych plików CDR bez deszyfrowania zawartości (Fully Homomorphic Encryption). Cel: CDR może weryfikować właściwości pliku bez dostępu do plaintext. Wyzwanie: performance FHE jest wciąż niewystarczający dla real-time processing. Kryterium porzucenia: jeśli latencja > 10x tradycyjnego CDR po 2 latach badań.

EXP-005 — Decentralized audit log (blockchain-based): Immutable audit log oparty na distributed ledger (nie publiczny blockchain — permissioned, np. Hyperledger Fabric). Cel: audit trail, którego integralność jest weryfikowalna bez zaufania do pojedynczego operatora. Wyzwanie: performance, complexity, czy rozwiązanie jest istotnie lepsze od hash chains w Zone 4.

19.10 Backlog autonomiczny

Status: [A] Autonomiczny Odbiorca: Architekt | Zarząd Wpływ na baseline: Średni (specyficzne use cases) Powiązane rozdziały: 19.8, 19.9

Backlog autonomiczny obejmuje elementy zaprojektowane dla specyficznych scenariuszy operacyjnych, w których standardowa architektura SYLION wymaga rozszerzeń. Elementy te mogą być rozwijane niezależnie od głównej roadmapy jako moduły opcjonalne.

AUTO-001 — Moduł rotacji IMSI: Dla operatorów działających w środowiskach o podwyższonym ryzyku surveillance (dziennikarze, aktywiści, personel dyplomatyczny) — moduł automatycznej rotacji IMSI karty SIM terminala. Rotacja oparta na profilu ryzyka: harmonogramowa (co N godzin), event-driven (zmiana lokalizacji, wykrycie IMSI catcher), manualna. Integracja z eSIM/eUICC (embedded SIM z multiple profiles). Wyzwanie: kompatybilność z operatorami telco, regulacje lokalne, latencja przełączenia profilu. Wymaga dedykowanego partnera telco lub MVNO.

AUTO-002 — Offline mesh fallback: W przypadku utraty łączności internetowej — automatyczne przełączenie na sieć mesh (Bluetooth LE, Wi-Fi Direct, LoRa) między terminalami SYLION w promieniu fizycznym. Tryb mesh: tylko komunikacja tekstowa Matrix (store-and-forward), bez workloadów chmurowych. Szyfrowanie: klucze pre-provisioned + protokół Double Ratchet. Cel: ciągłość komunikacji w scenariuszach kryzysowych (katastrofa naturalna, blackout, konflikt). Wyzwanie: zasięg, przepustowość, key management offline, synchronizacja po przywróceniu łączności.

AUTO-003 — Integracja Starlink: Dedykowany profil łączności dla terminali Starlink (LEO satellite), uwzględniający: wyższą latencję (~40-60ms), handoff między satelitami, zmienne IP, brak stałego AS. Konfiguracja IKEv2 z agresywnym DPD i MOBIKE, tuning TCP dla satelity, adaptive bitrate dla pixel streaming. Cel: operatorzy w lokalizacjach bez dostępnej infrastruktury naziemnej (misje polowe, statki, odległe lokalizacje). Wyzwanie: koszt, przepustowość w warunkach congestion, zależność od operatora (SpaceX — jurysdykcja US).

AUTO-004 — Moduł dead man switch: Automatyczny mechanizm bezpieczeństwa aktywowany po utracie kontaktu z operatorem przez zdefiniowany czas. Konfigurowalny per operator: po 24/48/72 godzinach bez heartbeat → alert SOC → freeze środowiska → opcjonalna rewokacja → powiadomienie designated contact person. Przeznaczony dla operatorów w środowiskach podwyższonego ryzyka (reporterzy w strefach konfliktu, whistleblowerzy). Deaktywacja: wymaga FIDO2 auth + kod bezpieczeństwa.

Rozdział 20. User journeys i mapy doświadczeń

20.1 Onboarding operatora

Status: [N] Normatywny Odbiorca: Klient | Partner | Infra | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 17.1, 17.4, 18.1, 18.11

Onboarding operatora to proces prowadzący od momentu decyzji o dodaniu nowej osoby do platformy SYLION do chwili, gdy operator przeprowadza pierwszą bezpieczną sesję roboczą. Proces musi zamknąć się w 3–4 godzinach.

Krok 1 — Utworzenie tożsamości (15 min). Administrator tenanta (Tenant Admin) inicjuje provisioning w management plane: tworzy tożsamość operatora w systemie IAM, przypisuje rolę (np. Operator Standard, Operator PRO), definiuje przynależność organizacyjną i atrybuty (oddział, lokalizacja, profil ryzyka). Jeśli tenant korzysta z federacji SSO, tożsamość SYLION jest powiązana z kontem w IdP klienta (Azure AD, Okta). System generuje unikalny identyfikator operatora i invitation token z TTL 24h.

Krok 2 — Enrollment MFA (15 min). Operator (lub wyznaczony Infra Admin) rejestruje klucz FIDO2. Dla STATE/SOVEREIGN: obowiązkowy fizyczny klucz (YubiKey 5 NFC lub równoważny). Dla STANDARD/PRO: FIDO2 lub TOTP jako minimum. Proces enrollment: operator skanuje QR code z invitation, uwierzytelnia się tymczasowymi credentials, rejestruje klucz FIDO2 (dotknięcie klucza generuje keypair). System generuje sealed recovery key (zaszyfrowany kluczem admina), przechowywany w HSM na wypadek utraty klucza FIDO2.

Krok 3 — Przygotowanie terminala (45 min). Infra Admin przygotowuje terminal: Pixel — flash GrapheneOS (verified build), instalacja klienta SYLION, konfiguracja profilu MDM, instalacja certyfikatu klienta IPsec (generowanego z HSM i wgrzanego do Titan M2). Laptop — instalacja hardened OS, enrollment w MDM, instalacja klienta VPN (strongSwan), instalacja klienta SYLION.

Krok 4 — Provisioning VPN (15 min). Management plane generuje konfigurację IPsec IKEv2 dla operatora: endpoint G1, certyfikat klienta (powiązany z tożsamością w IAM), parametry kryptograficzne. Konfiguracja jest pushowana na terminal via MDM lub transfer zaszyfrowany.

Krok 5 — Utworzenie środowiska operatora (30 min). IaC (Terraform) provisionuje: dedicated namespace, workloads (env-matrix, env-browser — minimum w MVP), network policies, egress rules, storage (encrypted volume), CDR profile. Środowisko jest tworzone z czystego obrazu — brak predefiniowanych danych.

Krok 6 — Testy akceptacyjne (30 min). Weryfikacja: tunel IPsec nawiązany → G1 terminacja OK → G2 device posture OK → session broker tworzy sesję → operator widzi workspace Matrix → test wysyłki wiadomości → test transferu pliku (CDR flow) → test logowania (event w Zone 4). Checklista podpisywana przez Infra Admin.

Krok 7 — Szkolenie operatora (60 min). Operator przechodzi szkolenie: korzystanie z klienta SYLION, bezpieczne praktyki (nie fotografuj ekranu, nie podłączaj USB, zamykaj sesję po pracy), procedura utraty urządzenia, procedura alarmowa. Potwierdzenie szkolenia logowane.

Pain points i jak SYLION je adresuje: Tradycyjny onboarding do bezpiecznej infrastruktury trwa dni/tygodnie. SYLION: automatyzacja IaC + standardowy terminal (Pixel) = < 4h. Brak konfiguracji po stronie operatora — terminal jest gotowy po jednorazowym setup.

20.2 Pierwsze logowanie

Status: [N] Normatywny Odbiorca: Klient | Dev | Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 18.1, 18.3, 18.5, 18.6, 22.1

Pierwsze logowanie stanowi moment, w którym operator po raz pierwszy doświadcza platformy SYLION w działaniu. Doświadczenie musi być płynne i szybkie — oczekiwany czas od dotyku klucza FIDO2 do wyświetlenia workspace'u Matrix: poniżej 3 sekund.

Krok 1 — Inicjacja uwierzytelnienia. Operator otwiera aplikację klienta SYLION na terminalu (Pixel/laptop). Ekran powitalny wyświetla: logo tenanta, pole identyfikatora operatora (pre-wypełnione jeśli terminal jest przypisany do jednego operatora), przycisk „Połącz” oraz status połączenia (offline/connecting/connected). Operator dotyka przycisk „Połącz”.

Krok 2 — FIDO2 challenge. Klient wyświetla prompt: „Dotknij klucz bezpieczeństwa”. Operator wkłada YubiKey NFC (dotknięcie tyłem Pixela) lub podłącza USB YubiKey na laptopie. Klucz FIDO2 podpisuje challenge od serwera uwierzytelniającego (IDP/IAM SYLION). Assertion jest przesyłana do IAM.

Krok 3 — Nawiązanie tunelu IPsec IKEv2. Po pomyślnym uwierzytelnieniu MFA, klient inicjuje tunel IPsec IKEv2 z G1. Fazy: IKE_SA_INIT (wymiana DH, uzgodnienie algorytmów) → IKE_AUTH (certyfikat klienta z Titan M2, certyfikat G1, EAP-TLS jeśli skonfigurowany) → CREATE_CHILD_SA (tunel ESP). Czas nawiązania: < 500ms w typowych warunkach sieciowych.

Krok 4 — Terminacja na G1 i przekazanie do G2. G1 terminuje IPsec, wykonuje inspekcję L3/L4 (rate limit check, anti-replay), loguje połączenie do Zone 4, i przekazuje ruch do G2 przez wewnętrzny kanał (wireline Zone 1 → Zone 2).

Krok 5 — Device posture evaluation na G2. G2 otrzymuje żądanie sesji i wykonuje: weryfikację tożsamości (token z IAM), ocenę device posture (wersja GrapheneOS, status FDE, hardware attestation result, ważność certyfikatu), ewaluację polityki kontekstowej (czas, lokalizacja sieciowa). Wynik: allow/deny/step-up. Czas ewaluacji: P99 < 10ms.

Krok 6 — Utworzenie sesji przez session broker. Po allow z G2, session broker tworzy sesję: alokuje kontekst sesji, łączy operatora z jego workloadami (env-matrix jako domyślny), inicjuje pixel streaming, otwiera kanał audio. Operator widzi ekran powitalny swojego workspace'u Matrix.

Krok 7 — Workspace gotowy. Operator widzi: okno Matrix z listą pokoi i historią rozmów (załadowaną z homeserver, nie z terminala), indyktor statusu połączenia (zielony = secure), indyktor MFA (FIDO2 active). Pierwsza wiadomość testowa: operator wysyła „test” w pokoju onboarding — wiadomość pojawia się natychmiast, E2EE ikona potwierdza szyfrowanie.

Łączny czas: < 3 sekundy od dotknięcia FIDO2 key do wyświetlenia workspace'u (przy stabilnym łączu i warm cache). Cold start (pierwszy login po provisioning): < 5 sekund (dodatkowy czas na inicjalizację workloadu).

20.3 Codzienna praca z komunikacją

Status: [R] Rekomendowany Odbiorca: Klient | Architekt | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 18.8, 18.10, 22.3

Typowy dzień pracy operatora SYLION z naciskiem na komunikację ilustruje, jak platforma łączy wysokie bezpieczeństwo z płynnym doświadczeniem użytkownika. Kluczowa zasada: operator nie powinien odczuwać, że pracuje w bezpiecznym środowisku — kompleksowość jest ukryta w infrastrukturze.

8:00 — Start sesji. Operator dotyka YubiKey NFC, klient SYLION nawiązuje tunel IPsec, G2 weryfikuje posture, session broker otwiera sesję. Operator widzi workspace Matrix z listą pokoi: #team-alpha, #project-x, #announcements. Nieprzeczytane wiadomości oznaczone standardowo (bold + counter). Czas od dotyku do workspace: < 3s.

8:05 — Komunikacja E2EE. Operator otwiera pokój #project-x i czyta wiadomości z nocy. Piszze odpowiedź — tekst pojawia się płynnie (latencja < 50ms E2E dla interaktywnego wejścia). Ikona kłódki potwierdza E2EE. Operator nie myśli o szyfrowaniu — po prostu pisze.

9:00 — Otrzymanie pliku. Kolega wysyła raport PDF w pokoju Matrix. Operator klika „Pobierz” — ale plik nie pojawia się natychmiast. Indykator: „Weryfikacja pliku...” (CDR processing). Po 5–15 sekundach plik jest dostępny (CDR: staging → efemeryczna microVM → rekonstrukcja → dostarczenie do env-matrix). Operator otwiera PDF — metadane usunięte, treść zachowana. Doświadczenie: minimalne opóźnienie, jasna komunikacja statusu.

10:00 — Rozmowa głosowa. Operator inicjuje voice call w Matrix (env-voice workload). Zielony indyktor: „Połączenie szyfrowane”. Jakość: latencja < 150ms, codec Opus. Operator rozmawia 20 minut — brak zakłóceń. Kończy call, wraca do tekstu.

12:30 — Przerwa. Operator blokuje terminal (ekran blokady). Po 2 minutach bez aktywności — auto-lock. Sesja SYLION: heartbeat kontynuuje (terminal → G1 keepalive), ale sesja jest w stanie idle. Operator nie musi się ponownie logować po odblokowaniu (w ramach TTL tokenu sesji).

14:00 — Współpraca w czasie rzeczywistym. Operator i kolega edytują notatki w pokoju Matrix (collaborative pad jeśli dostępny, lub wymiana wiadomości). Wszystko E2EE. Pliki wymieniane przechodzą CDR transparentnie.

17:00 — Koniec dnia. Operator zamyka aplikację SYLION lub wykonuje explicit logout. Tunel IPsec jest zamykany. Session broker terminuje sesję, loguje zakończenie do Zone 4. Na terminalu: zero danych roboczych. Brak historii wiadomości, brak plików, brak kluczy. Terminal jest czysty. Operator może bezpiecznie zostawić Pixela na biurku — nawet jeśli ktoś go weźmie, nie ma dostępu do żadnych danych organizacyjnych.

Kluczowe momenty bezpieczeństwa (niewidoczne dla operatora): Każde logowanie = weryfikacja FIDO2 + device posture. Każdy plik = CDR. Każda wiadomość = E2EE. Każdy heartbeat = weryfikacja żywotności sesji. Każda decyzja = log w Zone 4. Zero danych na terminalu po sesji.

20.4 Praca z dokumentami

Status: [R] Rekomendowany Odbiorca: Klient | Dev | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 18.7, 18.10, 22.3

Journey pracy z dokumentami w env-office ilustruje, jak operator tworzy, edytuje i eksportuje dokumenty w bezpiecznym środowisku SYLION.

Otwarcie dokumentu. Operator przełącza się z workspace Matrix na env-office (przycisk w kliencie SYLION lub skrót klawiszowy). Session broker publikuje okno LibreOffice Online (app-only publishing — operator nie widzi pulpitu Linux). Lista dokumentów: dokumenty w encrypted volume operatora, shared documents z tenanta (jeśli policy pozwala). Operator klika istniejący dokument .docx — otwiera się w edytorze.

Edycja. Operator edytuje dokument: wpisywanie tekstu, formatowanie, wstawianie tabeli. Doświadczenie zbliżone do natywnego LibreOffice — z latencją pixel streaming < 50ms dla interaktywnego tekstu. Autozapis co 60 sekund do encrypted volume. Wersjonowanie (jeśli skonfigurowane): każdy zapis tworzy wersję (snapshot volume lub git-like versioning w storage).

Współdzielenie w ramach tenanta. Operator chce udostępnić dokument koledze. Opcja: skopiować do shared folder tenanta (kontrolowanego polityką). Kolega widzi dokument na swojej liście. Brak transferu pliku — oba workloady operują na tym samym storage (tenant-level shared, z access control per operator). Alternatywa: wysyłka przez Matrix → plik przechodzi CDR (nawet wewnętrzny transfer).

Eksport dokumentu poza SYLION. Operator chce wysłać dokument na zewnątrz (np. klientowi). Proces: operator kliknie „Eksport” → plik trafia do CDR staging → CDR przetwarza (usunięcie metadanych, rekonstrukcja) → plik gotowy do pobrania na terminal → operator wysyła z terminala (email, komunikator zewnętrzny). W STATE/SOVEREIGN: eksport może wymagać approval admina (data loss prevention flow). Pełny audit trail: kto, co, kiedy, skąd, dokąd.

Tworzenie nowego dokumentu. Operator tworzy nowy dokument: wybiera typ (Writer, Calc, Impress), zaczyna pracę. Dokument istnieje wyłącznie w encrypted volume env-office. Nie na terminalu, nie w chmurze publicznej, nie na dysku współdzielonym z innymi workloadami.

Zamknięcie sesji. Operator zamyka env-office. Dokument zapisany w encrypted volume. Przy następnym logowaniu — dokument jest tam, gdzie go zostawił. Ale jeśli workload zostanie odbudowany (rebuild after anomaly) — dokument przetrwa, bo jest w dedicated persistent volume (nie w filesystem workloadu).

20.5 Praca z CRM i analityką

Status: [R] Rekomendowany Odbiorca: Klient | Dev | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 18.7, 22.3

Journey pracy z CRM (env-crm) ilustruje dostęp do danych klientów i generowanie raportów w kontrolowanym środowisku.

Dostęp do CRM. Operator przełącza się na env-crm. Session broker publikuje okno aplikacji CRM (konteneryzowanej). CRM łączy się z bazą danych klienta przez API (egress whitelist: wyłącznie API endpoint CRM). Operator widzi dashboard z kluczowymi metrykami: pipeline, recent activities, tasks.

Nawigacja i analiza. Operator przegląda profil klienta: dane kontaktowe, historia interakcji, dokumenty (pobierane z CRM storage → CDR jeśli przychodzą z zewnątrz). Generuje raport: np. „Pipeline value Q1 2026” — CRM przetwarza dane i wyświetla raport w przeglądarce workloadu.

Eksport raportu. Operator chce wyeksportować raport do PDF. CRM generuje PDF w filesystem workloadu. Jeśli operator chce przesłać PDF koledze (Matrix) — plik przechodzi CDR staging (nawet wewnętrzny transfer między workloadami). Jeśli operator chce pobrać PDF na terminal — CDR + polityka eksportu (DLP: czy ten typ danych może opuścić Zone 3?). W STATE/SOVEREIGN: eksport danych CRM wymaga approval admina.

Ograniczenia bezpieczeństwa. env-crm ma egress ograniczony do API CRM — nie ma dostępu do internetu (w przeciwieństwie do env-browser). Schowek z env-crm do env-matrix: text-only w STANDARD, zablokowany w STATE/SOVEREIGN. Screenshot env-crm: zablokowany w STATE/SOVEREIGN.

Dane wrażliwe. Dane CRM (dane osobowe klientów, dane handlowe) nigdy nie opuszczają Zone 3 bez jawnej akcji operatora + CDR + DLP + audit. W przypadku utraty terminala: zero danych CRM na urządzeniu. W przypadku offboarding operatora: dostęp do CRM natychmiast rewokowany, dane CRM pozostają w tenancie.

20.6 Przeglądanie internetu

Status: [R] Rekomendowany Odbiorca: Klient | Dev | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 18.7, 22.3

Journey przeglądania internetu w env-browser ilustruje, jak SYLION zapewnia bezpieczny dostęp do zasobów webowych.

Uruchomienie przeglądarki. Operator przełącza się na env-browser. Session broker publikuje okno Chromium/Firefox (hardened, w rootless container). Przeglądarka działa w workloadzie — cały rendering, JavaScript execution, network requests odbywają się w chmurze. Operator widzi tylko piksele.

Przeglądanie. Operator wpisuje URL — żądanie HTTP wychodzi z env-browser przez egress proxy (Zone 3 → egress → internet). Egress proxy: URL filtering (blokada znanych malicious sites, category filtering jeśli skonfigurowane), HTTPS inspection (jeśli polityka pozwala — z transparentnym CA wstrzykniętym do trust store przeglądarki), logging (URL, timestamp, operator, wynik). Strona łąduje się w przeglądarce workloadu → pixel streaming do terminala.

Pobieranie pliku. Operator klika link do pobrania pliku. Plik jest pobierany do filesystem env-browser → automatyczny CDR staging → przetwarzanie → jeśli operator chce przenieść plik do env-office, przechodzi CDR między workloadami. Jeśli chce pobrać na terminal — CDR + DLP. Każdy pobrany plik = audit trail.

Bezpieczeństwo. Exploit przeglądarki (drive-by download, zero-day) — atakujący uzyskuje dostęp do rootless container/microVM, nie do terminala operatora ani do innych workloadów. Container jest izolowany (seccomp, AppArmor, network policies). Automatyczny rebuild po wykrytej anomalii. Operator może kontynuować pracę w env-matrix podczas rebuildu env-browser (< 60 sekund).

Ograniczenia dla STATE/SOVEREIGN. W tierze STATE/SOVEREIGN: URL filtering bardziej restrykcyjny, HTTPS inspection obowiązkowe, download każdego pliku wymaga explicit approval, egress logowany z pełnym URL (nie tylko domain).

20.7 Zmiana urządzenia

Status: [N] Normatywny Odbiorca: Klient | Infra | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 18.1, 18.11, 20.1

Zmiana urządzenia (terminal swap) to proces, w którym operator przechodzi ze starego terminala na nowy — planowo (upgrade sprzętu) lub nieplanowo (uszkodzenie). Kluczowa cecha: ponieważ terminal nie przechowuje żadnych danych organizacyjnych, zmiana urządzenia jest operacją czysto infrastrukturalną.

Krok 1 — Rewokacja starego terminala (5 min). Admin inicjuje rewokację w management plane: certyfikat IPsec starego terminala jest unieważniany (CRL update, OSCP revocation), profil VPN jest dezaktywowany, profil MDM jest usuwany. Stary terminal nie może już nawiązać połączenia z G1 — jakiegokolwiek próby są blokowane i logowane.

Krok 2 — Przygotowanie nowego terminala (45 min). Infra Admin przygotowuje nowy terminal identycznie jak przy onboarding (Krok 3 z 20.1): flash GrapheneOS, instalacja klienta SYLION, konfiguracja MDM, wygenerowanie nowego certyfikatu klienta IPsec (powiązanego z tą samą tożsamością operatora, ale nowy keypair w nowym Titan M2).

Krok 3 — Re-enrollment FIDO2 (10 min). Operator musi ponownie zarejestrować klucz FIDO2 na nowym terminalu (jeśli FIDO2 jest roaming key — YubiKey — ten krok może nie być konieczny, bo klucz jest niezależny od terminala). Jeśli FIDO2 jest platform key (wbudowany w stary terminal) — wymaga re-enrollment z dual authorization: admin zatwierdza, operator rejestruje klucz na nowym terminalu.

Krok 4 — Provisioning VPN (15 min). Nowa konfiguracja IPsec (nowy certyfikat, ten sam endpoint G1) jest pushowana na nowy terminal via MDM.

Krok 5 — Weryfikacja i wznowienie pracy (15 min). Operator loguje się na nowym terminalu — pełny flow: FIDO2 → IPsec → G1 → G2 (device posture nowego terminala) → session broker → workspace. Wszystkie dane, workloady, historia Matrix — na miejscu, bo nigdy nie były na starym terminalu. Operator wznowia pracę, jakby nic się nie wydarzyło.

Bezpieczeństwo starego terminala. Stary terminal: opcjonalnie remote wipe (usunięcie profilu SYLION, certyfikatów). Nawet bez wipe: terminal nie zawiera danych organizacyjnych (Thin Client model). Certyfikat IPsec jest rewokowany — terminal jest bezużyteczny jako narzędzie dostępu.

Łączny czas: ~90 minut (przy przygotowanym spare terminal: ~30 minut).

20.8 Utrata urządzenia

Status: [N] Normatywny Odbiorca: Klient | SOC | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 18.1, 18.11, 20.7, 21.1

Utrata urządzenia (kradzież, zgubienie, konfiskata) to scenariusz kryzysowy, w którym szybkość reakcji jest kluczowa. Dzięki modelowi Thin Client, utrata terminala nie oznacza utraty danych — ale wymaga natychmiastowej rewokacji dostępu.

Minuta 0 — Zgłoszenie. Operator natychmiast kontaktuje SOC/admina: telefon na numer alarmowy, wiadomość z zapasowego urządzenia, lub zgłoszenie przez osobę trzecią (przełożony, kolega). Informacja: „Utraciłem terminal SYLION”.

Minuta 1–5 — Emergency revoke. Admin (lub SOC z uprawnieniem emergency) wykonuje natychmiastową rewokację: unieważnienie sesji (session broker terminuje wszystkie aktywne sesje operatora), unieważnienie tokenu MFA (FIDO2 credential powiązany z utraconym terminalem — dezaktywowany; roaming key jak YubiKey — osobna decyzja), rewokacja certyfikatu IPsec (CRL push, OSCP update), rewokacja profilu VPN. Cel: < 5 minut od zgłoszenia do pełnej rewokacji.

Minuta 5–15 — Cryptographic destroy (opcjonalne). Jeśli terminal wspiera remote wipe i jest online: wyzwolenie remote wipe (usunięcie profilu MDM, kluczy, konfiguracji). Jeśli terminal jest offline: wipe zakolejkowane, wykonane przy następnym połączeniu (ale rewokacja certyfikatu oznacza, że terminal i tak nie może się połączyć z SYLION).

Minuta 15–30 — Logowanie incydu. Operator (lub admin w imieniu operatora) loguje incydent: okoliczności utraty, typ urządzenia, przybliżony czas, lokalizacja. Incydent klasyfikowany: P2 (utrata kontrolowana, urządzenie zablokowane) lub P1 (podejrzenie kompromitacji, konfiskata przez adversarza).

Minuta 30–60 — Forensics. SOC analizuje logi Zone 4: ostatnia aktywność operatora, ostatnia znana lokalizacja sieciowa, czy nie nastąpiły nietypowe działania przed utratą (data exfiltration, unusual access patterns). Raport forensic.

Godzina 2–4 — Provisioning nowego terminala. Procedura jak w 20.7 (zmiana urządzenia). Operator otrzymuje nowy terminal, przechodzi re-enrollment i wznowia pracę.

Co jest bezpieczne po utracie: Dane organizacyjne — nigdy nie były na terminalu (Thin Client). Historia komunikacji — na homeserver Matrix, nie na terminalu. Dokumenty — w encrypted volume Zone 3, nie na terminalu. Klucze workloadów — w HSM, nie na terminalu. Jedyne ryzyko: klucz FIDO2 (jeśli platform key) i certyfikat IPsec (rewokowany). Atakujący z fizycznym dostępem do Pixela: GrapheneOS + FDE + Titan M2 = wysoka bariera ekstrakcji.

20.9 Scenariusz awaryjny — operator pod przymusem

Status: [R] Rekomendowany Odbiorca: SOC | Zarząd | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 18.11, 19.10, 21.10

Scenariusz kryzysowy obejmuje sytuacje, w których operator jest aresztowany, zatrzymany, porwany lub w inny sposób pozbawiony swobody działania. Platforma SYLION musi posiadać mechanizmy ochronne działające bez aktywnego udziału operatora.

Dead man switch — automatyczna detekcja. Mechanizm heartbeat terminala: klient SYLION regularnie wysyła heartbeat do session broker (interwał konfigurowalny: domyślnie co 5 minut). Jeśli heartbeat nie dociera przez zdefiniowany czas (konfigurowalny per operator: 24h, 48h, 72h), system aktywuje procedurę dead man switch.

Faza 1 — Alert (po X godzinach bez heartbeat). SOC otrzymuje alert P1: „Operator [ID] — heartbeat timeout”. SOC podejmuje próbę kontaktu z operatorem przez kanały alternatywne (telefon osobisty, kontakt awaryjny, przełożony). Jednocześnie: środowisko operatora jest zamrażane (freeze — brak możliwości eksportu danych, brak możliwości nowych operacji, istniejące sesje zachowane w read-only).

Faza 2 — Eskalacja (po potwierdzeniu braku kontaktu). Jeśli kontakt z operatorem niemożliwy: management plane freeze środowiska operatora (nie tenanta — innych operatorów nie dotyczy). Powiadomienie wyznaczonej osoby kontaktowej (designated contact person — konfigurowane przy onboarding). Opcjonalnie: pełna rewokacja tożsamości operatora (zależnie od polityki tenanta i severity sytuacji).

Faza 3 — Sealed recovery. Jeśli operator odzyskuje wolność i potrzebuje wrócić do pracy: procedura sealed recovery key — dual authorization admin + operator z recovery key → re-enrollment FIDO2 → nowy terminal → odmrożenie środowiska. Jeśli operator nie wraca: po zdefiniowanym czasie (np. 30 dni) — archiwizacja środowiska i deprovisioning.

Duress code (opcjonalny, eksperymentalny). Możliwość skonfigurowania kodu przymusu (duress PIN/gesture): operator uwierzytelnia się specjalnym kodem, który wygląda na normalne logowanie, ale w rzeczywistości: wyświetla ograniczony, „czysty” workspace (sandbox), jednocześnie wysła cichą alert P1 do SOC, rozpoczyna procedurę containment. Wyzwanie: wiarygodność sandbox (musi wyglądać jak normalny workspace), ryzyko fałszywych alarmów.

Ochrona danych. W każdym scenariuszu awaryjnym: dane operatora pozostają zaszyfrowane w Zone 3, chronione kluczami z HSM. Fizyczny dostęp do terminala nie daje dostępu do danych. Wymuszenie uwierzytelnienia pod przymusem — nawet przy prawidłowym FIDO2 — nie ujawnia danych, jeśli admin zdążył zamrozić środowisko. Atakujący widzi co najwyżej sesję read-only lub sandbox.

20.10 Offboarding operatora

Status: [N] Normatywny Odbiorca: Klient | Infra | Compliance | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.1, 18.11, 23.4

Offboarding operatora to pełna rewokacja dostępu i zniszczenie środowiska operatora. Proces musi być zakończony w czasie < 15 minut (od decyzji do braku dostępu) z pełnym audit trail.

Krok 1 — Decyzja i inicjacja (1 min). Tenant Admin inicjuje offboarding w management plane. System wyświetla podsumowanie: operator ID, aktywne sesje, aktywne workloady, dane w storage. Admin potwierdza offboarding (dual authorization dla STATE/SOVEREIGN).

Krok 2 — Natychmiastowa rewokacja dostępu (< 5 min). Automatyczna kaskada: dezaktywacja tożsamości w IAM → unieważnienie tokenów MFA (wszystkie FIDO2 credentials operatora) → rewokacja certyfikatu IPsec (CRL push, OCSP revocation) → terminacja wszystkich aktywnych sesji (session broker force-disconnect) → zablokowanie dostępu do wszystkich workloadów. Od tego momentu operator nie może się zalogować.

Krok 3 — Archiwizacja logów (5 min). Logi aktywności operatora w Zone 4 są archiwizowane z tagiem „offboarded” i retencją zgodną z polityką (minimum 2 lata). Logi są integralną częścią compliance trail i nie podlegają usunięciu przy offboardingu.

Krok 4 — Zniszczenie lub archiwizacja środowiska (5 min). W zależności od polityki tenanta: zniszczenie — workloady terminowane, namespace usunięty, encrypted volume zniszczony (crypto-shredding: zniszczenie klucza szyfrującego volume), storage wymazany; archiwizacja — workloady terminowane, volume snapshot zaszyfrowany i przeniesiony do archive storage (Zone 4), dostępny wyłącznie dla audytorów z uprawnieniem. Wybór: konfigurowalne per tenant, per rola operatora.

Krok 5 — Terminal cleanup (parallel). Jeśli terminal jest zwracany do organizacji: remote wipe profilu SYLION, re-provisioning terminala (factory reset + nowy setup) lub przechowanie do ponownego użycia. Jeśli terminal jest prywatny operatora: remote wipe profilu SYLION, certyfikaty usunięte, klient odinstalowany.

Krok 6 — Evidence of data deletion (5 min). System generuje evidence: raport z listą zniszczonych zasobów (volume ID, namespace, certyfikaty), hash potwierdzający crypto-shredding (klucz zniszczony → dane nieodzyskiwalne), timestamp, wykonujący admin. Raport przechowywany w Zone 4 jako evidence GDPR compliance (Art. 17).

Weryfikacja post-offboarding. Automated test: próba logowania z credentials operatora → denied; próba dostępu do workloadów → not found; weryfikacja, że namespace usunięty; weryfikacja, że volume zniszczony lub zarchiwizowany. Test logowany jako evidence.

20.11 Journey administratora

Status: [R] Rekomendowany Odbiorca: Klient | Infra | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 18.13, 22.1, 23.3

Typowy dzień administratora platformy SYLION obejmuje operacje provisioning, monitorowania i reagowania na zdarzenia — wszystko w ścisłym reżimie audytowalności.

8:30 — Login admina. Admin łączy się z management plane przez bastion host: FIDO2 auth → session recording aktywowane → session TTL 4h → workspace adminowy. Interface: dashboard z KPI (active operators, sessions, alerts, CDR queue, health status komponentów).

9:00 — Provisioning nowego operatora. Ticket od HR: nowy pracownik. Admin uruchamia workflow provisioning: tworzy tożsamość → przypisuje rolę → generuje invitation → koordynuje z Infra (przygotowanie terminala). IaC tworzy środowisko operatora. Admin monitoruje postęp na dashboardzie provisioning.

10:00 — Review alertów. Admin przegląda alerty z nocy: 2x failed login (brute force? → sprawdzenie logów → operator zapomniał PIN → cleared), 1x CDR quarantine (plik .exe w attachment Matrix z federacji → quarantine correct → no action), 1x performance alert (latencja G2 P99 > 15ms → sprawdzenie → traffic spike → auto-scaled → resolved). Każdy alert: review, classify, action, close. Logowane w Zone 4.

11:00 — Zmiana polityki. Tenant wymaga zmiany: zablokować clipboard z env-browser do env-matrix. Admin: pisze policy change w Rego/Cedar → peer review (drugi admin) → automated test (positive + negative case) → deploy via CI/CD → policy hot-reload na G2 → weryfikacja (test clipboard blocked) → close change request. Audit trail: before/after diff, approver, test result, deployment timestamp.

14:00 — Dual authorization. Inny admin żąda rotacji certyfikatu intermediate CA. Notification: „Admin B requests intermediate CA rotation — approve?”. Admin A reviewuje: powód (scheduled rotation), impact assessment, rollback plan. Approve → operacja wykonana → audit record z obu podpisami.

16:00 — Offboarding. Ticket od HR: pracownik odchodzi. Admin inicjuje offboarding (20.10). Weryfikuje: rewokacja complete, workspace destroyed, evidence generated. Zamyka ticket z evidence.

20.12 Journey SOC / Incident Response

Status: [N] Normatywny Odbiorca: SOC | Architekt | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 18.14, 21.1, 23.7

Journey SOC analityka obejmuje pełny cykl incident response — od alertu przez analizę, containment, eradication, do recovery i lessons learned.

Alert triage. SIEM generuje alert P2: „Operator X — anomalny wzorec egress z env-browser: 500 requests/min do single IP outside normal baseline”. SOC analityk otwiera alert w SIEM → korelacja z logami G2 (operator X, env-browser, egress proxy logs) → timeline: od 14:32 operator przegląda stronę, od 14:35 JavaScript na stronie generuje high-frequency requests → assessment: prawdopodobnie cryptominer/beacon w przeglądarce, nie działanie operatora.

Investigation. SOC drills down: Zone 4 logi → pełny URL history env-browser operatora X w ostatniej godzinie → identyfikacja strony źródłowej → analiza DNS queries → weryfikacja, czy inne workloady operatora X są czyste (Matrix, office — brak anomalii, izolacja działu). Correlation ID łączy alert z sesją i workloadem.

Containment (automated + manual). Automated: system już zablokował egress do suspicious IP (anomaly detection rule). Manual: SOC decyduje o rebuild env-browser operatora X → trigger rebuild → nowa microVM z czystego obrazu → < 60 sekund downtime. Operator X: widzi krótkie „Reconnecting...” i kontynuuje

pracę w czystej przeglądarce.

Eradication. SOC: dodaje malicious URL do blacklist egress proxy → deploy → weryfikacja, że URL jest blokowany. Analiza: czy inni operatorzy odwiedzali tę stronę? → query Zone 4 → 2 operatorów → rebuild ich env-browser przewencyjnie.

Recovery. Operator X: pełna funkcjonalność przywrócona (< 5 minut od alertu). Żadne dane nie wyciekły (cryptominer/beacon nie miał dostępu do danych — env-browser nie ma dostępu do env-matrix ani env-crm). Brak lateral movement.

Post-incident. SOC generuje incident report: timeline, root cause, actions taken, impact assessment (none — containment successful), recommendations (improve URL filtering, add cryptominer detection rule). Report w Zone 4 z chain of custody.

20.13 Journey partnera / integratora

Status: [R] Rekomendowany Odbiorca: Partner | Zarząd | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 17.5, 19.2

Journey partnera/integratora obejmuje cykl od wdrożenia platformy u klienta, przez bieżące zarządzanie, po eskalację i wsparcie.

Faza 1 — Pre-sales i design (1–2 tygodnie). Partner otrzymuje brief od klienta: „potrzebujemy bezpiecznej komunikacji dla 50 operatorów, sektor finansowy, Polska”. Partner konfiguruje: tier PRO, data residency PL (eu-central), workloady: env-matrix, env-browser, env-office, env-crm. Partner tworzy design document z: architekturą, politykami, harmonogramem, kosztorysem. Review z zespołem SYLION (Partner API: validate configuration).

Faza 2 — Deployment (3–5 dni). Partner inicjuje deployment via Partner API: provisioning tenanta, konfiguracja IAM federation (klient: Azure AD), provisioning G1/G2 w regionie PL, deployment workloadów (IaC — Terraform modules dostarczane przez SYLION). Partner konfiguruje: polityki CDR, egress rules, monitoring integration (klient ma Splunk → SYLION eksportuje logi do Splunk HEC).

Faza 3 — Onboarding operatorów (1–2 tygodnie). Partner koordynuje onboarding 50 operatorów: przygotowanie terminali (batch provisioning: 50 Pixeli z GrapheneOS), enrollment FIDO2, szkolenia. Partner API umożliwia automatyzację: batch create identities, batch generate invitations, batch provision VPN configs. Szkolenie: partner prowadzi warsztaty (materiały dostarczane przez SYLION).

Faza 4 — Managed service (ongoing). Partner monitoruje platformę klienta: dashboard per tenant (Partner API), alerty (eskalacja P1/P2 do SYLION L3, P3/P4 obsługiwane przez partnera), monthly reviews z klientem. Partner wykonuje: patching (koordynacja z SYLION release schedule), provisioning/deprovisioning operatorów (na zlecenie klienta), policy changes (z peer review).

Faza 5 — Eskalacja. Klient zgłasza problem: „latencja sesji wzrosła”. Partner: triage (sprawdzenie metryk G1/G2/session broker via Partner API), diagnoza (network path analysis, telemetry review). Jeśli problem w infrastrukturze SYLION: eskalacja do SYLION L2/L3 z pełnym kontekstem (logi, metryki, timeline). SYLION rozwiązuje, partner komunikuje klientowi.

Rozdział 21. Tryby degradacji i scenariusze awaryjne produktu

21.1 Degradacja warstwy dostępowej

Status: [N] Normatywny Odbiorca: Infra | SOC | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.4, 18.2, 18.3, 20.8

Degradacja warstwy dostępowej obejmuje scenariusze, w których operator traci łączność z G1 — awaria routera, ISP, sieć lokalna, lub awaria samego G1.

Co ulega awarii. Tunel IPsec IKEv2 jest zrywany: DPD (Dead Peer Detection) wykrywa brak odpowiedzi peera w ciągu timeout (domyślnie 90 sekund). Klient SYLION: status zmienia się na „Rozłączono” z informacją „Utrata połączenia z siecią SYLION”.

Co kontynuuje działanie. Po stronie chmury: workloady operatora działają normalnie, sesja w session broker jest zachowana w stanie „disconnected — awaiting reconnect” przez konfigurowalny czas (domyślnie 5 minut dla STANDARD, 15 minut dla STATE). Dane operatora (Matrix history, dokumenty) — bezpieczne w Zone 3. Po stronie terminala: zero danych organizacyjnych (Thin Client). Kill switch blokuje ruch poza tunel — brak ryzyka wycieku ruchu organizacyjnego do sieci publicznej.

Wpływ na użytkownika. Operator widzi: ekran „Rozłączono — trwa próba ponownego połączenia”. Brak możliwości pracy, brak dostępu do komunikacji, brak dostępu do dokumentów. Ważne: operator nie traci żadnych danych — po ponownym połączeniu sesja jest przywracana (w ramach grace period).

Automatyczna reakcja. Klient SYLION: retry automatyczny (eksponencjalny backoff: 2s, 4s, 8s, 16s, max 60s). Jeśli MOBIKE jest skonfigurowane: automatyczna próba na alternatywnym interfejsie (Wi-Fi —> LTE). Jeśli G1 HA: failover do passive node (< 5s), klient re negocjuje tunel z nowym G1. SOC: alert o disconnect operatora (po 5 minutach — P3; po 15 minutach — P2).

Interwencja manualna. Operator: sprawdzenie łączności lokalnej, restart routera, przełączenie na sieć zapasową. Admin: jeśli awaria G1 — weryfikacja HA failover, restart G1 jeśli potrzebny (rebuild z IaC < 10 min). ISP failure: brak kontroli SYLION — operator musi użyć alternatywnej sieci.

Czas recovery. Network recovery (ISP/LAN): zależny od zewnętrznego dostawcy. G1 failover: < 5 sekund (HA). G1 rebuild: < 10 minut. Session reconnect po przywróceniu łączności: < 5 sekund (w ramach grace period, bez re-auth). Poza grace period: pełny re-auth (FIDO2 + IPsec).

21.2 Degradacja session broker

Status: [N] Normatywny Odbiorca: Infra | SOC | Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 18.6, 21.1, 21.3

Session broker zarządza cyklem życia sesji. Jego degradacja wpływa na zdolność nawiązywania nowych sesji i — w zależności od architektury — na istniejące sesje.

Co ulega awarii. Session broker primary staje się niedostępny (crash, network partition, resource exhaustion). Przyczyny: bug w oprogramowaniu, wyczerpanie pamięci (memory leak), awaria VM/container.

Co kontynuuje działanie. Istniejące sesje pixel streaming mogą kontynuować — jeśli broker pełni jedynie rolę session establishment (nie uczestniczy w aktywnym strumieniu). W architekturze, gdzie broker utrzymuje session state (tokens, heartbeat, policy refresh) — istniejące sesje kontynuują z cached state do momentu TTL tokenu. G1, G2 — działają normalnie. Workloady — działają normalnie. Zone 4 logging — działa normalnie.

Wpływ na użytkownika. Nowe sesje: operator próbuje się zalogować → FIDO2 OK → IPsec OK → G2 OK → session broker → timeout → „Nie można nawiązać sesji, spróbuj ponownie za chwilę”. Istniejące sesje: kontynuują normalnie (do TTL tokenu) lub doświadczają graceful degradation (ograniczona funkcjonalność — np.

brak nowych workloadów).

Automatyczna reakcja. HA: failover do secondary broker (active-passive: < 2 minuty; active-active z load balancer: seamless — utrata jednego node'a, load przejmują pozostałe). Health check wykrywa niedostępność (co 5 sekund), trigger failover. Alert P2 do SOC. Auto-restart crashed brokera (Kubernetes liveness probe → restart pod → <30 sekund).

Interwencja manualna. SOC: diagnoza root cause (logi, metryki, core dump jeśli crash). Admin: jeśli HA failover niewystarczający — manual failover, lub rebuild brokera z IaC. Post-mortem: analiza przyczyny, fix, deploy.

Czas recovery. Auto-restart (Kubernetes): < 30 sekund. HA failover: < 2 minuty. Rebuild z IaC: < 15 minut. Wpływ na nowe połączenia: 0–2 minuty (z HA). Wpływ na istniejące sesje: minimalny (kontynuują z cached state).

21.3 Degradacja workloadu

Status: [N] Normatywny Odbiorca: Infra | SOC | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 18.7, 21.2

Degradacja pojedynczego workloadu (crash microVM/container, resource exhaustion, detected anomaly) to najczęstszy scenariusz awarii w codziennej operacji.

Co ulega awarii. Jeden workload jednego operatora (np. env-browser operatora X) crashuje lub jest terminowany (anomaly detection trigger, OOM kill, bug w aplikacji).

Co kontynuuje działanie. Wszystkie inne workloady tego samego operatora (env-matrix, env-office) — działają normalnie (izolacja per-workload). Workloady innych operatorów — całkowicie niezatknięte (izolacja per-operator, dedykowane namespace). G1, G2, session broker, Zone 4 — bez wpływu.

Wpływ na użytkownika. Operator widzi: okno crashed workloadu znika lub wyświetla „Trwa przywracanie usługi...” z indykátorem postępu. Inne okna (Matrix, Office) — działają normalnie. Po < 60 sekundach: workload jest odbudowany z czystego obrazu, operator widzi nowe okno. Dane persystentne (dokumenty w env-office, jeśli w dedicated volume) — zachowane. Dane efemeryczne (stan przeglądarki, otwarte karty) — utracone.

Automatyczna reakcja. Session broker wykrywa brak heartbeat od workloadu (timeout 30s) → trigger rebuild: nowy container/microVM z obrazu (pull image, deploy, mount persistent volume, start, health check) → < 60 sekund. Nowy workload jest automatycznie podłączany do sesji operatora. Alert P3 do SOC z root cause (OOM, anomaly, crash signal). Jeśli workload crashuje > 3 razy w ciągu 1 godziny: eskalacja P2, tymczasowe wyłączenie workloadu, notyfikacja operatora i admina.

Interwencja manualna. Jeśli auto-rebuild nie pomaga: SOC/admin diagnozuje (logi workloadu, metryki, core dump). Potencjalne przyczyny: bug w aplikacji (→ patch), resource contention (→ reschedule na inny node), uszkodzony obraz (→ rebuild image pipeline). Operator: może kontynuować pracę w innych workloadach podczas diagnozy.

Czas recovery. Auto-rebuild: < 60 sekund. Persistent data recovery: natychmiastowa (volume mount). Ephemeral data: utracona. Impact na operatora: < 60 sekund downtime jednego workloadu. Impact na innych: zero.

21.4 Degradacja usług współdzielonych

Status: [N] Normatywny Odbiorca: Infra | SOC | Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 18.8, 18.10, 21.3

Usługi współdzielone (CDR, Matrix homeserver, DNS resolver, egress proxy) obsługują wielu operatorów. Ich degradacja ma potencjalnie szerszy wpływ.

CDR processing degradation. Przyczyna: queue overflow (duży wolumen plików), crash CDR microVM orchestrator, awaria storage staging. Efekt: pliki wchodzące do Zone 3 są kolejowane — operatorzy widzą „Weryfikacja pliku — dłuższy czas oczekiwania”. Pliki nie są tracone (queue durable). Praca tekstowa (Matrix messages, browsing) — bez wpływu. Security posture: utrzymany — żaden plik nie wchodzi bez CDR, nawet z opóźnieniem. Automatyczna reakcja: scaling CDR workers (Kubernetes HPA), alert P2 jeśli queue > 100 plików lub latencja > 5 minut. Recovery: scaling resolves queue w < 10 minut.

Matrix homeserver degradation. Przyczyna: database issue (PostgreSQL), memory pressure, disk full. Efekt: operatorzy widzą opóźnienia w dostarczeniu wiadomości lub „Serwer komunikacyjny niedostępny”. Inne workloady (browser, office, CRM) — działają normalnie. Automatyczna reakcja: HA (Synapse workers + HAProxy), restart crashed workers, alert P2. Recovery: restart worker < 30 sekund, database recovery < 5 minut. Federacja: jeśli federacja aktywna — remote homeservers queue messages, dostarczają po recovery.

DNS resolver degradation. Przyczyna: resolver crash, upstream DNS failure. Efekt: workloady nie mogą rozwiązywać nazw → egress nie działa (browser offline, CRM API failed), Matrix federation offline. Security: nie ma wpływu na istniejące połączenia (cached DNS), nowe połączenia blocked. Automatyczna reakcja: failover do secondary resolver, alert P2. Recovery: < 30 sekund (failover).

Egress proxy degradation. Przyczyna: proxy crash, overload. Efekt: env-browser nie ładuje stron, env-signal nie łączy z Signal infrastructure. Inne workloady (wewnętrzne, bez egress) — bez wpływu. Automatyczna reakcja: HA proxy (active-active), auto-restart, alert P2. Recovery: < 30 sekund.

21.5 Degradacja management plane

Status: [N] Normatywny Odbiorca: Infra | SOC | Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 18.13, 21.1

Management plane (Zone 5) degradation jest jednym z najpoważniejszych scenariuszy, ponieważ wpływa na zdolność zarządzania platformą — ale nie na bieżącą operację.

Co ulega awarii. Bastion host, Terraform state backend, Vault (secrets), management API, monitoring dashboard, IaC pipeline. Przyczyny: awaria regionu chmurowego, compromise attempt (→ auto-freeze), software failure.

Co kontynuuje działanie. Wszystkie istniejące sesje operatorów — działają normalnie. G1, G2 — działają z cached politykami. Session broker — kontynuuje. Workloady — bez wpływu. Zone 4 logging — kontynuuje. CDR — kontynuuje. Cała operacyjna ścieżka danych działa bez management plane.

Wpływ na użytkownika. Operatorzy: brak wpływu na bieżącą pracę. Admini: nie mogą: provisionować nowych operatorów, decommissionować operatorów (chyba że pre-scheduled), zmieniać polityk, wykonywać rotacji kluczy, deployować aktualizacji. Krytyczne: nie mogą wykonać emergency revoke standardową drogą.

Automatyczna reakcja. Platforma automatycznie wchodzi w tryb freeze: wszystkie istniejące polityki obowiązują, brak zmian. Alert P1 do SOC (management plane unreachable). Failover management plane do DR region (jeśli multi-region). Jeśli compromise detected: auto-lockdown.

Interwencja manualna. Break-glass procedure: admin z sealed credentials (fizyczny sejf, HSM-stored) → dostęp awaryjny do management plane via backup bastion → diagnoza → restore lub rebuild. Break-glass: testowany kwartalnie, dokumentacja offline. Dla emergency revoke bez management plane: pre-provisioned kill switch per operator (API endpoint w G2, uwierzytelniony break-glass credentials).

Czas recovery. DR failover: < 30 minut (pre-provisioned DR region). Rebuild z IaC: < 2 godziny (from scratch). Break-glass access: < 15 minut (physical access to credentials required).

21.6 Degradacja voice/video

Status: [R] Rekomendowany Odbiorca: Infra | Klient Wpływ na baseline: Średni Powiązane rozdziały: 18.7, 22.3

Degradacja usług voice/video (env-voice) wpływa na zdolność komunikacji głosowej i wideo, ale nie na pozostałe kanały.

Co ulega awarii. SRTP stream nie może być nawiązany lub istniejące streamy są przerywane. Przyczyny: awaria media servera, network congestion (jitter, packet loss > 5%), resource exhaustion workloadu voice.

Co kontynuuje działanie. Cała komunikacja tekstowa Matrix — bez wpływu. Workloady env-browser, env-office, env-crm — bez wpływu. CDR, IAM, G1/G2 — bez wpływu. Operator może kontynuować pracę tekstową.

Wpływ na użytkownika. Połączenie głosowe/wideo: zrywa się. Operator widzi: „Połączenie głosowe zakończone — problem z siecią”. Próba ponownego połączenia: „Usługa głosowa tymczasowo niedostępna, korzystaj z czatu tekstowego”. Graceful degradation: system proponuje fallback na komunikację tekstową Matrix (ta sama konwersacja, kontynuacja w tekście).

Automatyczna reakcja. Media server: HA (active-active, load balanced), auto-restart crashed instance (< 30s). Codec adaptation: jeśli packet loss > 1% → reduce bitrate (Opus: 16 kbps → 8 kbps), switch from wideband to narrowband. Jitter buffer: adaptive (50ms → 200ms). Alert P3 (performance) lub P2 (full outage) do SOC.

Interwencja manualna. SOC/Infra: diagnoza (network path analysis, media server metrics, operator network quality). Jeśli network congestion: nic do zrobienia po stronie SYLION — operator musi poprawić lokalne warunki sieciowe. Jeśli server-side: scaling, restart, rebuild.

Czas recovery. Media server restart: < 30 sekund. Network-related: zależny od warunków. Reconnect call: natychmiastowy po recovery serwera.

21.7 Degradacja integracji zewnętrznych

Status: [R] Rekomendowany Odbiorca: Infra | Klient | Partner Wpływ na baseline: Średni Powiązane rozdziały: 18.7, 18.9, 21.4

Integracje zewnętrzne (CRM API, Signal infrastructure, external SIEM, IdP federation) są zależne od systemów poza kontrolą SYLION.

CRM API niedostępny. Efekt: env-crm wyświetla: „Nie można połączyć z systemem CRM — dane mogą być nieaktualne”. Jeśli CRM ma local cache w workloadzie: dane read-only dostępne (stale data). Write operations: queued for retry. Inne workloady: bez wpływu. Recovery: automatyczny retry z exponential backoff. Alert P3 do admina tenanta.

Signal infrastructure niedostępna. Efekt: env-signal: „Usługa Signal tymczasowo niedostępna”. Operator nie może wysyłać/odbierać wiadomości Signal. Matrix (env-matrix): działa normalnie — operator może kontynuować komunikację wewnętrzną. Recovery: automatyczny retry. Alert P3 (informacyjny — zależność zewnętrzna).

IdP federation niedostępna (Azure AD, Okta down). Efekt: nowe logowania operatorów korzystających z tego IdP — niemożliwe. Istniejące sesje: kontynuują (token z long-lived session). Operatorzy z local FIDO2 (nie zależnym od IdP): mogą się logować. Mitygacja: local authentication fallback (FIDO2 as primary, IdP as optional attribute source). Recovery: automatyczny po przywróceniu IdP.

External SIEM niedostępny (Splunk, Sentinel down). Efekt: logi nie docierają do SIEM klienta. Logi SYLION: bezpieczne — Zone 4 logging kontynuuje niezależnie. Buffer: logi do SIEM są buforowane (durable queue, retention 72h). Po recovery SIEM: logi są dostarczane z bufora (no data loss). Alert P3 do admina.

21.8 Tryb read-only

Status: [R] Rekomendowany Odbiorca: SOC | Infra | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 18.13, 21.5, 21.10

Tryb read-only jest aktywowany w odpowiedzi na zdarzenie bezpieczeństwa, maintenance window lub jako etap pośredni w eskalacji incydentu. Zapewnia ciągłość pracy informacyjnej przy jednoczesnej ochronie przed modyfikacją lub eksportem danych.

Trigger aktywacji. Automatyczny: wykrycie incydentu P1 (np. anomalny wzorec eksportu danych), freeze management plane, scheduled maintenance. Manualny: decyzja SOC/admin o przejściu w tryb read-only (np. na czas dochodzenia forensic).

Co działa. Operatorzy mogą: czytać wiadomości Matrix (historię), przeglądać dokumenty (read-only), przeglądać dane CRM (read-only), przeglądać internet (env-browser — bez download). Operatorzy nie mogą: wysyłać wiadomości, edytować dokumentów, eksportować plików (CDR staging zablokowany), wykonywać operacji CRM write. Indykator: jasny banner w kliencie SYLION: „Tryb ograniczony — system w trybie tylko do odczytu”.

Wpływ na użytkownika. Operator widzi ograniczenia: próba wysłania wiadomości → „Operacja niedostępna w trybie ograniczonym”. Nie traci danych. Nie jest rozłączany. Może kontynuować review informacji.

Automatyczna reakcja. Przejście w read-only: Policy Engine na G2 przełącza politykę globalną (lub per-tenant, per-operator) na read-only profile. Zmiana jest natychmiastowa (policy hot-reload). Logi: zdarzenie „READ_ONLY_MODE_ACTIVATED” z: trigger, scope (global/tenant/operator), activator (system/admin), timestamp.

Wyjście z read-only. Wymaga: dual authorization (dwóch adminów), jeśli trigger był security event — SOC clearance (incydent zamknięty lub eskalowany z akceptacją ryzyka). Log: „READ_ONLY_MODE_DEACTIVATED” z pełnym kontekstem.

21.9 Częściowy tryb offline

Status: [R] Rekomendowany Odbiorca: Infra | SOC | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 17.6, 21.1, 21.5

Częściowy tryb offline obejmuje scenariusze, w których niektóre regiony lub strefy dostępności (availability zones) są niedostępne, podczas gdy inne działają normalnie.

Scenariusz: awaria regionu. Region eu-central (Frankfurt) doświadcza outage (cloud provider issue, network partition, power failure). Tenanci z data residency „EU — dowolny region”: automatyczny failover do eu-west (Amsterdam/Paryż). Tenanci z data residency „DE-only”: brak failover — sesje zawieszone do przywrócenia regionu (data residency constraint ma priorytet nad dostępnością).

Co działa w regionach nieobjętych awarią. Pełna funkcjonalność: operatorzy w nieobjętych regionach pracują normalnie. Żaden wpływ na ich sesje, workloady, CDR, logi.

Wpływ na użytkowników w objętym regionie. Operatorzy: „Nie można nawiązać połączenia — trwa przywracanie usługi”. Brak dostępu do pracy. Dane: bezpieczne (encrypted storage w regionie, backup w DR region). Po failover (dla tenantów bez restrykcji): operatorzy łączą się z DR regionem — sesja nowa (nie kontynuacja), ale workloady i dane dostępne (z RPO ≤ 24h konfiguracji, dane persystentne z continuous replication).

Automatyczna reakcja. Health check regionu: monitoring endpoint per region, check co 30 sekund. Region declared unhealthy po 3 consecutive failures → trigger failover workflow: DNS update (GeoDNS → redirect to DR region), provisioning standby (jeśli hot standby) lub cold start (jeśli warm standby), notification: operatorzy w affected region → „Trwa przełączanie na region zapasowy, reconnect za [ETA]”.

Czas recovery. Hot standby (STATE/SOVEREIGN): < 15 minut (pre-provisioned infrastruktura, data replicated). Warm standby (PRO): < 1 godzina (infrastruktura pre-configured, data restore z backup). Cold start (STANDARD): < 4 godziny (full provisioning from IaC + data restore). Region recovery (primary): zależny od cloud provider — SYLION monitoruje i wykonuje failback gdy region jest stable (po 24h stability window).

21.10 Awaryjny tryb minimalny

Status: [N] Normatywny Odbiorca: SOC | Zarząd | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 18.13, 20.9, 21.5, 21.8

Awaryjny tryb minimalny (Emergency Minimal Mode) to najwyższy poziom degradacji kontrolowanej — aktywowany w scenariuszach kryzysowych, w których utrzymanie pełnej funkcjonalności jest niemożliwe lub ryzykowne.

Trigger aktywacji. Scenariusze: potwierdzony breach (atakujący w infrastrukturze), katastrofalna awaria wielu komponentów jednocześnie, cyberatak na dużą skalę (DDoS + exploitation), kompromitacja management plane. Aktywacja: automatyczna (system detects cascading failures) lub manualna (SOC/CISO decision).

Co działa. Minimum viable security posture: IAM (uwierzytelnianie, rewokacja — musi działać, aby można było odciąć atakującego), podstawowa komunikacja Matrix (env-matrix — E2EE text only, bez plików, bez voice), Zone 4 logging (musi działać — forensic evidence), G1/G2 (z uproszczoną polityką — allow known operators, deny everything else). Management plane: freeze (no changes possible without break-glass).

Co jest wyłączone. Nieistotne workloady: env-browser, env-office, env-crm, env-signal, env-voice — wszystkie suspended. CDR: disabled (brak transferu plików). Federacja Matrix: disabled (izolacja). External integrations: disabled. Monitoring: ograniczony do security events.

Wpływ na użytkownika. Operatorzy widzą: „Tryb awaryjny — dostępna wyłącznie komunikacja tekstowa”. Mogą: wysyłać i odbierać wiadomości Matrix (E2EE). Nie mogą: otwierać dokumentów, przeglądać internetu, korzystać z CRM, transferować plików. Cel: utrzymanie podstawowej komunikacji kryzysowej.

Zdefiniowany security posture. W trybie minimalnym: Zero Trust nadal obowiązuje (FIDO2 + device posture). E2EE nadal aktywne. Logi nadal zbierane. Izolacja tenantów nadal wymuszona. Brak kompromisu na fundamentalnych zasadach bezpieczeństwa — wyłączane są usługi dodatkowe, nie kontrole bezpieczeństwa.

Wyjście z trybu minimalnego. Wymaga: SOC clearance (incident contained lub eradicated), dual authorization (CISO + Platform Admin), post-incident review initiated. Powrót jest stopniowy: najpierw G2 full policy → CDR → workloady jeden po drugim → federacja → integracje. Każdy krok weryfikowany przed przejściem do następnego.

Czas w trybie minimalnym: Nie zdefiniowany — zależy od nature incydentu. Oczekiwany: godziny (nie dni). Jeśli > 24h: eskalacja do Zarządu z decyzją o dalszych krokach.

Rozdział 22. Dostępność, użyteczność i internacjonalizacja

22.1 Wymagania UX wysokiego poziomu

Status: [N] Normatywny Odbiorca: Dev | Architekt | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 17.2, 18.6, 20.2, 22.2

Filozofia UX platformy SYLION opiera się na zasadzie niewidocznego bezpieczeństwa: operator musi doświadczać platformy jak zwykłego narzędzia pracy — szybkiego, responsywnego, intuicyjnego. Kompleksowość kryptograficzna, izolacja workloadów, CDR, Zero Trust — wszystko to musi być ukryte za prostym, „nudnym” interfejsem. Termin „nudny” jest tu komplementem — oznacza, że bezpieczeństwo nie przeszkadza w pracy.

Kluczowe zasady UX wysokiego poziomu obejmują trzy filary. Pierwszy to szybkość: czas od uwierzytelnienia do wyświetlenia sesji roboczej musi wynosić poniżej 3 sekund w warunkach typowego połączenia (> 10 Mbps, < 50 ms RTT). Drugi filar to przejrzystość statusu — operator musi w każdej chwili widzieć: status połączenia VPN (aktywne/przerwane), aktywność sesji, wynik ostatniego uwierzytelnienia MFA, oraz ewentualne ostrzeżenia systemowe. Trzeci filar to minimalizm — interfejs klienta terminalowego nie zawiera żadnych funkcji poza niezbędnymi do obsługi sesji zdalnej.

Platforma musi stosować spójny język wizualny (design system) obejmujący palety kolorów, typografię, ikony statusów, wzorce nawigacji. Każdy tier (STANDARD, PRO, STATE) może mieć własne warianty kosmetyczne, ale logika interakcji musi być identyczna — operator przeszkolony na STANDARD powinien bezzwłocznie obsługiwać STATE bez dodatkowego szkolenia (z wyjątkiem różnic wynikających z polityk bezpieczeństwa, np. braku schowka).

Metryki UX podlegające monitorowaniu: czas do pierwszej sesji (onboarding TTF), czas logowania (auth-to-session), liczba kroków do wykonania typowej operacji (send message, open document, export file), współczynnik błędów użytkownika (misclick, retry, timeout). Metryki te muszą być zbierane anonimowo i w sposób nieinwazyjny, wyłącznie do celów optymalizacji produktu, nigdy do profilowania operatorów.

Interfejs musi być testowany z użytkownikami o różnym poziomie kompetencji technicznych — od specjalistów IT po operatorów biurowych. Wynik: platforma SYLION powinna być obsługiwana przez operatora po maksymalnie 30-minutowym szkoleniu wprowadzającym.

22.2 Minimalizm klienta terminalowego

Status: [N] Normatywny Odbiorca: Dev | Architekt | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 18.1, 20.2, 22.1

Aplikacja kliencka SYLION na terminalu operatora (Pixel/GrapheneOS lub zarządzany laptop) musi realizować wyłącznie następujące funkcje: zarządzanie tunelem IPsec IKEv2 (nawiazanie, utrzymanie, heartbeat), interfejs uwierzytelniania FIDO2 (dialog z kluczem sprzętowym), wyświetlanie strumienia pikseli z sesji zdalnej, obsługa wejścia/wyjścia audio, minimalny wskaźnik schowka (clipboard), wyświetlanie statusu połączenia i zdrowia sesji.

Aplikacja kliencka nie zawiera i nie implementuje: lokalnego menadżera plików, lokalnego magazynu danych, launchera aplikacji, przeglądarki, klienta pocztowego, jakiegokolwiek komponentu przetwarzającego dane biznesowe. Terminal jest wyłącznie „oknem” do zdalnego środowiska — cieniem klientem w pełnym tego słowa znaczeniu.

Architektura klienta opiera się na trzech warstwach: warstwa transportowa (biblioteka IPsec, certyfikaty), warstwa prezentacji (dekoder strumienia pikseli, kodek audio, obsługa inputu), warstwa zarządzania (konfiguracja, logowanie diagnostyczne, update klienta). Każda warstwa jest izolowana — awaria warstwy prezentacji nie powoduje wycieku danych z warstwy transportowej.

Aktualizacje klienta muszą być automatyczne i podpisane cyfrowo. Klient przed uruchomieniem weryfikuje integralność własnego kodu (secure boot chain na GrapheneOS, podpis binarki na laptopie). Klient nie akceptuje konfiguracji z niezauważanego źródła — konfiguracja jest dostarczana wyłącznie przez management plane i podpisana kluczem infrastrukturalnym.

Klient musi działać poprawnie w warunkach ograniczonej łączności: automatyczny reconnect po przerwie, buforowanie inputu do 5 sekund, wizualne wskazanie degradacji jakości obrazu. W przypadku całkowitej utraty łączności klient nie przechowuje żadnych danych sesyjnych — po rozłączeniu terminal jest czysty, tak jakby sesja nigdy nie istniała.

Minimalny footprint klienta: <50 MB na dysku, <100 MB RAM w trakcie sesji, <5% CPU w stanie idle. Te limity zapewniają, że terminal pozostaje responsywny nawet na urządzeniach o ograniczonych zasobach.

22.3 Ergonomia operacyjna

Status: [N] Normatywny Odbiorca: Dev | Architekt | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 17.2, 20.3, 22.1, 22.7, 22.8

Ergonomia operacyjna platformy SYLION musi spełniać wymagania pozwalające na komfortową wielogodziną pracę bez odczuwalnych różnic w stosunku do pracy na urządzeniu lokalnym. Kluczowe parametry ergonomiczne dzielą się na trzy kategorie: latencja interakcji, jakość audio/video, responsywność wizualna.

Latencja interakcji — czas od naciśnięcia klawisza lub dotknięcia ekranu do widocznej reakcji w strumieniu pikseli — musi wynosić poniżej 50 ms end-to-end dla pracy tekstowej. Dla operacji graficznych (przewijanie, rysowanie) akceptowalny próg to 80 ms. Powyżej 100 ms operator zaczyna odczuwać opóźnienie, co jest niedopuszczalne dla codziennej pracy. Platforma musi dynamicznie dostosowywać parametry kodowania (bitrate, rozdzielczość, częstotliwość klatek) do warunków sieciowych, priorytetyzując niską latencję kosztem jakości obrazu.

Jakość audio — kluczowa dla komunikacji głosowej (env-voice) — musi zapewniać latencję poniżej 150 ms (one-way), packet loss poniżej 1%, oraz wykorzystywać kodeki Opus z adaptive bitrate. Jakość musi być wystarczająca do wielogodzinnych rozmów operacyjnych. Echo cancellation i noise suppression muszą działać po stronie serwera, nie terminala.

Responsywność wizualna obejmuje: płynne przewijanie (minimum 30 FPS dla tekstu, 24 FPS dla video), natychmiastową reakcję na zmianę fokusa między workloadami, czytelność tekstu na wszystkich obsługiwanych rozdzielczościach (minimum 720p dla mobile, 1080p dla desktop). Klient musi obsługiwać skalowanie DPI (HiDPI/Retina) bez utraty ostrości tekstu.

Platforma musi zapewniać mechanizm feedback'u użytkownika: jeśli latencja przekracza akceptowalne progi, operator widzi subtelny wskaźnik jakości połączenia (np. pasek zmieniający kolor). Nigdy nie blokujemy interfejsu bez informacji — każde oczekiwanie musi mieć wizualny indyktor.

Testy ergonomiczne muszą być prowadzone z udziałem rzeczywistych operatorów minimum raz na kwartał, z pomiarem Task Completion Time (TCT), System Usability Scale (SUS, cel: >75), oraz Net Promoter Score (NPS) wewnętrznego.

22.4 Dostępność interfejsu administracyjnego

Status: [R] Rekomendowany Odbiorca: Dev | Architekt | Compliance Wpływ na baseline: Średni Powiązane rozdziały: 17.2, 22.1, 23.1

Panel administracyjny SYLION — wykorzystywany przez administratorów tenantów, operatorów SOC oraz inżynierów infrastruktury — musi spełniać wymagania dostępności cyfrowej zgodne ze standardem WCAG 2.1 na poziomie AA. Wymaganie to dotyczy wszystkich interfejsów webowych management plane, w tym dashboardów monitoringu, paneli zarządzania użytkownikami, konfiguratorów polityk i narzędzi audytowych.

Kontrast tekstu musi spełniać minimalne progi: 4.5:1 dla tekstu standardowego, 3:1 dla tekstu dużego (18px+ lub 14px bold). Wszystkie elementy interaktywne (przyciski, linki, pola formularzy) muszą być dostępne z klawiatury — nawigacja Tab, aktywacja Enter/Space, nawigacja w listach strzałkami. Focus ring musi być zawsze widoczny i wyraźny.

Formularze administracyjne muszą posiadać: etykiety powiązane z polami (label + for/aria-labelledby), komunikaty błędów powiązane z polami (aria-describedby), logiczną kolejność tabulacji, wsparcie dla autouzupełniania (autocomplete attributes). Tabele danych (logi, listy operatorów, sesje) muszą używać semantycznego HTML (

, umożliwiać sortowanie z klawiatury, oraz posiadać opisy tabel (caption lub aria-label).

Interaktywne wykresy i wizualizacje danych muszą posiadać alternatywne reprezentacje: tabele danych jako fallback, opisy tekstowe (alt text) dla statycznych wykresów, ARIA live regions dla aktualizacji w czasie rzeczywistym. Kolor nigdy nie może być jedynym nośnikiem informacji — każdy status musi mieć również etykietę tekstową lub ikonę.

Panel musi obsługiwać dwa schematy kolorystyczne: jasny (domyślny) i ciemny (system preference lub ręczne przełączenie). Oba schematy muszą spełniać wymagania kontrastowe WCAG AA.

Testy dostępności muszą być częścią pipeline'u CI/CD: automatyczne (axe-core lub pa11y) dla każdego merge request, manualne (z czytnikiem ekranu NVDA/VoiceOver) minimum raz na kwartał. Raport z testów dostępności musi być dostępny na żądanie klienta, szczególnie dla wdrożeń w sektorze publicznym.

22.5 Obsługa wielojęzyczności

Status: [R] Rekomendowany Odbiorca: Dev | Klient | Partner Wpływ na baseline: Średni Powiązane rozdziały: 17.2, 22.1, 22.6

Platforma SYLION musi obsługiwać wielojęzyczny interfejs użytkownika zarówno na poziomie klienta terminalowego, jak i panelu administracyjnego. Minimalne wymagane lokalizacje to: polski (PL) — język podstawowy, angielski (EN) — język międzynarodowy, niemiecki (DE) — rynek DACH, francuski (FR) — rynek frankofoński i instytucje UE. Dodatkowe lokalizacje mogą być dodawane modularnie przez partnerów integracyjnych.

Architektura i18n musi opierać się na standardzie ICU MessageFormat lub kompatybilnym (i18next, FormatJS) z pełnym wsparciem dla: pluralizacji (polskie zasady: 1, 2-4, 5-21, 22-24...), rodzajów gramatycznych, formatowania liczb (separatory tysięcy/dziesiątne), formatowania dat i godzin (lokalne formaty), formatowania walut. Łańcuchy tekstowe muszą być wyekstrahowane do plików zasobów (JSON/XLIFF), nigdy zakodowane w kodzie źródłowym.

Proces tłumaczenia musi obejmować: wyeksportowanie kluczy z kodu (automatyzacja CI), tłumaczenie przez natywnego tłumacza (nie wyłącznie maszynowe), review kontekstowy (tłumacz widzi klucz w interfejsie), testy regresji wizualnej (dłuższe tłumaczenia niemieckie nie mogą „rozjeżdżać” layoutu), weryfikacja kompletności (100% pokrycia przed release). Tłumaczenia maszynowe mogą być używane jako pierwsza wersja (draft), ale muszą przejść review manualny przed produkcją.

Interfejs musi obsługiwać dynamiczne przełączanie języka bez restartu sesji. Wybór języka jest per-user setting, nie per-tenant — w jednym tenancie operatorzy mogą pracować w różnych językach. Logi systemowe i komunikaty bezpieczeństwa są zawsze w EN (język kanoniczny dla SIEM i audytu), niezależnie od wyboru języka interfejsu.

Dokumentacja produktowa (podręcznik operatora, podręcznik administratora, procedury awaryjne) musi być dostępna minimum w PL i EN. Dokumentacja techniczna (architektura, API reference) wyłącznie w EN.

22.6 Lokalizacja formatów danych

Status: [R] Rekomendowany Odbiorca: Dev | Klient Wpływ na baseline: Niski Powiązane rozdziały: 22.5, 17.2

Lokalizacja wykracza poza tłumaczenie etykiet — obejmuje prawidłowe formatowanie danych prezentowanych operatorom i administratorom. Platforma SYLION musi respektować lokalne konwencje formatowania w warstwie prezentacji, zachowując jednolity format kanoniczny w warstwie danych i logów.

Daty i godziny: wyświetlane w strefie czasowej operatora (ustawienie per-user), w formacie lokalnym (PL: dd.MM.yyyy HH:mm, EN: MM/dd/yyyy hh:mm AM/PM, DE: dd.MM.yyyy HH:mm). Wszystkie znaczniki czasu w logach, API i bazach danych muszą być przechowywane w UTC (ISO 8601: yyyy-MM-ddTHH:mm:ssZ). Konwersja odbywa się wyłącznie w warstwie prezentacji. Panel administracyjny musi pozwalać na wyświetlanie zarówno czasu lokalnego, jak i UTC (przełącznik).

Liczby: separatory tysięcy i dziesiątne zgodne z lokalizacją (PL: 1 234,56; EN: 1,234.56; DE: 1.234,56). W eksportach CSV/JSON zawsze format kanoniczny (punkt dziesiętny, bez separatora tysięcznego).

Formaty plików: eksportowane raporty (PDF, XLSX) muszą respektować lokalizację wybraną przez administratora generującego raport — format dat, liczb, nagłówki kolumn w wybranym języku. Formaty importowane muszą być rozpoznawane automatycznie lub z jawnym wskazaniem lokalizacji źródła.

Strefy czasowe muszą być obsługiwane poprawnie w scenariuszach multi-region: operator w Polsce widzi czas warszawski, administrator w Berlinie widzi czas berliński, audit log pokazuje UTC. Korelacja zdarzeń w SIEM odbywa się wyłącznie na podstawie UTC, nigdy czasu lokalnego. Baza danych stref czasowych musi być aktualizowana (tzdata) co najmniej raz na kwartał, aby uwzględnić zmiany legislacyjne (np. zmiana czasu letniego).

Waluta: jeśli platforma wyświetla informacje kosztowe (dashboard rozliczeniowy), kwoty muszą być prezentowane w walucie kontraktu z odpowiednim formatowaniem lokalnym. Kalkulacje wewnętrzne zawsze w walucie bazowej (EUR).

22.7 Wymagania specyficzne dla urządzeń mobilnych

Status: [N] Normatywny Odbiorca: Dev | Architekt | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 17.2, 18.1, 22.1, 22.3

Terminal mobilny (Pixel z GrapheneOS) stanowi podstawowy wariant urządzenia w architekturze SYLION. Klient terminalowy na urządzeniu mobilnym musi spełniać specyficzne wymagania ergonomiczne i techniczne wynikające z charakterystyki platformy mobilnej.

Obsługa dotyku: interfejs sesji zdalnej musi poprawnie mapować gesty dotykowe na zdarzenia myszy/klawiatury w workloadach serwerowych. Minimum: tap = kliknięcie, long press = prawy przycisk, dwupalcowe przesuwanie = przewijanie, pinch = zoom (jeśli workload obsługuje). Klawiatura ekranowa musi być wywołana automatycznie przy fokusie na pole tekstowe w sesji zdalnej. Obsługa klawiatury fizycznej (Bluetooth) musi działać transparentnie.

Zarządzanie energią: heartbeat (sygnał do management plane potwierdzający aktywność terminala) musi być frequency-aware — w trybie aktywnej pracy heartbeat co 30 sekund, w trybie tła (ekran wyłączony) heartbeat co 5 minut z wykorzystaniem mechanizmów oszczędzania baterii (WorkManager/AlarmManager na Android). Klient nie może powodować nadmiernego drenażu baterii — cel: <5% baterii na godzinę aktywnej sesji, <1% na godzinę w tle.

Obsługa zmiennych warunków sieciowych: klient mobilny musi obsługiwać handoff między Wi-Fi a LTE/5G bez zrywania sesji VPN (IKEv2 MOBIKE). Tunel IPsec musi automatycznie negocjować ponownie po zmianie interfejsu sieciowego. Czas przywrócenia sesji po handoff: <2 sekundy. Klient musi adaptować parametry strumienia pikseli do dostępnej przepustowości — redukcja bitrate, obniżenie FPS, przejście do trybu niższej rozdzielczości.

Orientacja ekranu: klient musi obsługiwać tryb portretowy i krajobrazowy. Workloady desktopowe (env-office, env-browser) mogą wymuszać tryb krajobrazowy z komunikatem dla operatora. Komunikacja (env-matrix) musi działać komfortowo w trybie portretowym.

Notyfikacje push: klient może wyświetlać powiadomienia o przychodzących wiadomościach (metadata, nie treść), ale powiadomienia muszą przechodzić przez kanał push z minimalną ekspozycją metadanych — wyłącznie „masz nową wiadomość”, bez nadawcy, tematu, fragmentu.

22.8 Wymagania specyficzne dla urządzeń desktopowych

Status: [N] Normatywny Odbiorca: Dev | Architekt | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 17.2, 18.1, 22.1, 22.3

Terminal desktopowy (zarządzany laptop z hardened OS) stanowi alternatywny wariant urządzenia, szczególnie dla operatorów wymagających wielogodzinnej pracy z dokumentami, CRM lub zaawansowanymi narzędziami analitycznymi. Klient terminalowy na desktopie musi spełniać wymagania wynikające z większych możliwości sprzętowych i ergonomicznych platformy.

Obsługa wielu monitorów: klient musi pozwalać na wyświetlanie różnych workloadów na różnych monitorach — env-matrix na monitorze głównym, env-office na dodatkowym. Każdy workload jest osobną sesją pikseli, niezależnie skalowalną. Rozdzielczość każdego monitora musi być obsługiwana natywnie (do 4K/5K), z automatycznym wykrywaniem DPI i skalowaniem. Zmiana konfiguracji monitorów (podłączenie/odłączenie) musi być obsługiwana gracefully — sesja nie jest przerywana, workloady relayout się automatycznie.

Skróty klawiszowe: klient musi przekazywać pełne sekwencje klawiszy do sesji zdalnej, w tym kombinacje systemowe (Ctrl+Alt+Del, Alt+Tab w kontekście workloadu). Klient musi definiować meta-skróty do przełączania między workloadami (np. Super+1..9) oraz skrót powrotu do klienta (np. Ctrl+Shift+Esc). Skróty muszą być konfigurowalne przez administratora w ramach polityki.

Zarządzanie schowkiem: na deszkopie schówek jest kluczowym narzędziem pracy. Polityka schowka musi być egzekwowana granularnie: kopiuj tekst (tak/nie per para workloadów), kopiuj obraz (tak/nie), kopiuj plik (zawsze przez CDR), rozmiar maksymalny (np. 1 MB). Każda operacja schowka musi być logowana (źródło, cel, rozmiar, typ, timestamp). W tier STATE/SOVEREIGN schówek między workloadami jest domyślnie wyłączony.

Drukowanie: kontrolowane przez politykę. Jeśli dozwolone — drukowanie odbywa się przez serwer wydruku w infrastrukturze SYLION (nie bezpośrednio na drukarkę lokalną). Zadanie druku przechodzi CDR. Jeśli zabronione — opcja drukowania jest ukryta w interfejsie, nie tylko zablokowana.

Wydajność: desktop klient musi wykorzystywać GPU acceleration do dekodowania strumienia pikseli (VA-API/NVDEC), minimalizując obciążenie CPU. Cel: <10% CPU przy 1080p60, <20% przy 4K30.

22.9 Ograniczenia ergonomii w trybach high-security

Status: [N] Normatywny Odbiorca: Dev | Architekt | Klient | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 18.6, 22.1, 22.3, 23.1

W tierach o podwyższonym bezpieczeństwie (STATE/SOVEREIGN) platforma SYLION wymusza ograniczenia ergonomiczne, które są świadomym kompromisem między wygodą a bezpieczeństwem. Ograniczenia te muszą być jasno komunikowane operatorom podczas onboardingu i udokumentowane w materiałach szkoleniowych.

Schowek między workloadami: całkowicie wyłączony. Operator nie może kopiować tekstu, obrazów ani plików między env-matrix a env-office. Transfer danych między workloadami wymaga eksplicitnego procesu: eksport z workloadu źródłowego do CDR staging, przetworzenie CDR, import do workloadu docelowego. Proces jest świadomie wielokrokowy — stanowi kontrolę bezpieczeństwa, nie wadę systemu.

Zrzuty ekranu: zablokowane na poziomie klienta. API zrzutów ekranu systemu operacyjnego terminala musi być wyłączone (na GrapheneOS: per-app screen capture policy, na laptopie: systemowa polityka DLP). Próba wykonania zrzutu ekranu musi być logowana jako zdarzenie bezpieczeństwa i może generować alert.

Re-autentykacja FIDO2: wymagana co 8 godzin pracy ciągłej (czas mierzony od ostatniego uwierzytelnienia). Dodatkowo re-autentykacja wymagana przy: wznowieniu sesji po >15 minutach nieaktywności, próbie eksportu pliku, próbie dostępu do workloadu o wyższej klasyfikacji. Dialog re-autentykacji musi być nieinwazyjny (nie powoduje utraty kontekstu pracy), ale obligatoryjny.

Drag-and-drop: całkowicie wyłączony. Pliki nie mogą być przeciągane między workloadami ani z/do terminala. Każdy transfer plików musi przejść przez CDR z jawnym zatwierdzeniem operatora. To ograniczenie eliminuje wektor ataku social engineering, w którym operator nieświadomie przenosi zainfekowany plik.

Sesja nagrywana (opcjonalnie per polityka tenanta): w STATE/SOVEREIGN tenant może włączyć nagrywanie sesji pikseli (screen recording po stronie serwera). Operator jest o tym informowany za pośrednictwem stałego wskaźnika wizualnego (ikona nagrywania). Nagrania przechowywane w Zone 4, dostępne wyłącznie do celów audytowych z autoryzacją dual-approval.

Szkolenie: każdy operator w tier STATE/SOVEREIGN musi przejść szkolenie obejmujące: przyczyny ograniczeń (dlaczego brak schowka, dlaczego CDR), procedury pracy w ograniczonym środowisku (jak transferować dane między workloadami), procedury awaryjne. Szkolenie musi być udokumentowane i odnotowane w systemie IAM jako warunek dostępu.

Rozdział 23. Wymagania audytowalności i zgodności

23.1 Audytowalność decyzji systemu

Status: [N] Normatywny Odbiorca: Compliance | SOC | Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 17.8, 18.5, 18.14

Każda decyzja systemu SYLION — rozumiana jako weryfikacja polityki bezpieczeństwa skutkująca zezwoleniem lub odmową dostępu — musi generować niemodyfikowalny rekord audytowy. Dotyczy to w szczególności decyzji podejmowanych przez G2 (Policy Engine), session broker, moduł CDR oraz system IAM. Rekord audytowy decyzji musi być kompletny, samowystarczalny (zrozumiały bez kontekstu zewnętrznego) oraz nieodwracalnie zapisany.

Każdy rekord decyzji musi zawierać następujące pola: znacznik czasu (timestamp UTC, zsynchronizowany NTP, z dokładnością do milisekund), identyfikator decydenta (komponent systemu: G2, session-broker, CDR-engine, IAM), typ decyzji (ALLOW, DENY, STEP-UP, QUARANTINE), polityka ewaluowana (ID polityki, wersja, hash reguły), atrybuty wejściowe (operator ID, device posture score, żądany zasób, kontekst — lokalizacja, czas, typ sieci), wynik (szczegóły decyzji, przyczyna odmowy jeśli DENY), identyfikator korelacji (trace ID łączący decyzję z sesją i innymi zdarzeniami).

Format rekordu musi być ustrukturyzowany (JSON), ze zdefiniowanym schematem (JSON Schema opublikowany w dokumentacji API). Rekordy muszą być zapisane do Zone 4 (WORM storage) w ciągu 5 sekund od momentu podjęcia decyzji. Eksport do zewnętrznego SIEM musi nastąpić w ciągu 60 sekund.

Integralność rekordów musi być zabezpieczona łańcuchem hashów (hash chain) — każdy rekord zawiera hash poprzedniego rekordu, tworząc niezaprzeczalną sekwencję. Łamanie łańcucha jest wykrywane automatycznie i generuje alert P1.

Retencja rekordów decyzji: minimum 2 lata (wymóg regulacyjny GDPR audit trail), z możliwością przedłużenia per tenant (np. 7 lat dla sektora finansowego). Usunięcie rekordów przed upływem retencji jest technicznie niemożliwe (WORM).

Dostęp do rekordów decyzji jest dwupoziomowy: administrator tenanta widzi decyzje dotyczące swoich operatorów (filtrowane po tenant ID), operator SOC SYLION widzi metadane techniczne (bez danych operatora). Separacja ta jest egzekwowana kryptograficznie — rekordy tenanta są zaszyfrowane kluczem tenanta, metadane techniczne kluczem SOC.

23.2 Audytowalność sesji i działań operatora

Status: [N] Normatywny Odbiorca: Compliance | SOC | Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 17.8, 18.6, 20.3, 23.1

Każda sesja operatora w platformie SYLION — od momentu uwierzytelnienia do zakończenia — generuje ciągły strumień zdarzeń audytowych. Zdarzenia te muszą umożliwiać pełną rekonstrukcję chronologiczną sesji bez dostępu do treści komunikacji. Granica między telemetrią bezpieczeństwa a monitoringiem treści musi być jednoznaczna, udokumentowana i kontraktowo zdefiniowana.

Zdarzenia sesyjne podlegające obowiązkowej rejestracji: połączenie (connect — timestamp, source IP/network type, terminal ID, device posture score), uwierzytelnienie (MFA event — metoda, wynik, czas), heartbeat (okresowe potwierdzenie aktywności terminala — interwał, status), uruchomienie workloadu (launch — workload type, timestamp, resource allocation), zakończenie workloadu (stop — przyczyna: operator, timeout, error, admin kill), rozłączenie (disconnect — przyczyna: operator logout, idle timeout, heartbeat failure, admin revoke, network loss).

Zdarzenia działań operatora: żądanie transferu pliku (file transfer request — workload źródłowy, typ pliku, rozmiar, hash, decyzja CDR), próba eksportu (export attempt — cel, decyzja polityki), zdarzenie schowka (clipboard event — kierunek, typ danych, rozmiar, decyzja polityki), zmiana workloadu (workload switch — z którego na który, timestamp).

Zdarzenia wyraźnie NIEREJESTROWANE (privacy boundary): treść wiadomości w Matrix (E2EE — platforma technicznie nie ma dostępu), treść dokumentów w env-office, treść wyświetlana na ekranie (strumień pikseli), treść rozmów głosowych. Ta granica nie jest opcjonalna — jest to fundamentalne zobowiązanie architektoniczne platformy SYLION i musi być uwzględniona w każdej umowie z klientem.

Korelacja zdarzeń: każda sesja posiada unikalny session ID, który łączy wszystkie zdarzenia tej sesji. Session ID jest powiązany z operator ID i terminal ID, ale te powiązania są dostępne wyłącznie w kontekście audytowym (nie w bieżącym monitoringu). Korelacja cross-session (ten sam operator, różne sesje) jest możliwa wyłącznie przez administratora tenanta z uprawnieniem AUDIT_READ.

Retencja zdarzeń sesyjnych: 2 lata (domyślna, WORM), konfigurowalna per tenant do 7 lat. Po upływie retencji dane są usuwane kryptograficznie (key deletion).

23.3 Audytowalność operacji administracyjnych

Status: [N] Normatywny Odbiorca: Compliance | SOC | Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.8, 18.13, 20.11, 23.1

Każda operacja administracyjna — definiowana jako działanie wykonane przez osobę z uprawnieniem wykraczającym poza standardowe uprawnienia operatora — musi generować kompletny rekord audytowy obejmujący pełny łańcuch autoryzacji. Operacje administracyjne stanowią najwyższe ryzyko nadużycia uprawnień i dlatego podlegają najsurowszym wymaganiom audytowym.

Rekord operacji administracyjnej musi zawierać: kto (administrator ID, rola, uprawnienie użyte), co (typ operacji, obiekt docelowy, parametry), kiedy (timestamp UTC), skąd (source IP, terminal ID, bastion session ID), dlaczego (ticket/CR number — wymagane dla wszystkich operacji destrukcyjnych), kto zatwierdził (approver ID dla operacji dual-approval), wynik (sukces/porażka, szczegóły błędu).

Operacje podlegające dual-approval (wymagające zatwierdzenia drugiej osoby z uprawnieniem ADMIN_APPROVE): usunięcie operatora, usunięcie tenanta, zmiana polityki bezpieczeństwa, rotacja klucza root/intermediate CA, zmiana konfiguracji G1/G2, włączenie/wyłączenie trybu freeze, dostęp break-glass, eksport logów audytowych. Dual-approval musi być realizowany synchronicznie (zatwierdzający musi potwierdzić w ciągu 30 minut) lub asynchronicznie (kolejka z eskalacją po timeout).

Operacje destrukcyjne (usunięcie danych, usunięcie tożsamości, wyczyszczenie logów) muszą posiadać: 24-godzinne okno cofnięcia (soft delete), potwierdzenie po upływie okna (hard delete wymaga ponownego zatwierdzenia), pełny rekord w Zone 4 (rekord samego usunięcia jest nieusuwany).

Anomalie administracyjne podlegające automatycznemu alertowi: operacja poza standardowymi godzinami pracy administratora, seria operacji na wielu tenantach w krótkim czasie, operacja z nieznanego terminala/IP, nieudane próby dual-approval (retry pattern), operacja na obiekcie oznaczonym jako „sensitive” (np. klucz, polityka root).

Raportowanie: system musi generować tygodniowy raport aktywności administracyjnej (podsumowanie operacji, anomalie, statystyki dual-approval) dostępny dla Chief Security Officer tenanta i SYLION Security Team.

23.4 Audytowalność provisioningu i deprovisioningu

Status: [N] Normatywny Odbiorca: Compliance | SOC | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.1, 18.11, 20.1, 20.10, 23.3

Cykl życia każdego obiektu zarządzanego w platformie SYLION — operatora, tenanta, workloadu, certyfikatu, polityki — musi posiadać pełny, niemodyfikowalny ślad audytowy od momentu utworzenia do momentu zniszczenia. Audytowalność provisioningu jest kluczowa dla wykazania zgodności z regulacjami (GDPR art. 30 — rejestr czynności przetwarzania) oraz dla forensics (rekonstrukcja, kto miał dostęp do czego i kiedy).

Provisioning operatora generuje następujący łańcuch audytowy: żądanie utworzenia (requestor ID, uzasadnienie, ticket reference), zatwierdzenie (approver ID, timestamp), utworzenie tożsamości (operator ID, rola, tenant, timestamp), enrollment MFA (metoda, urządzenie, timestamp), provisioning VPN (certyfikat ID, ważność, gateway przypisany), utworzenie środowiska operatora (namespace, workloady, zasoby), aktywacja (pierwsza sesja, potwierdzenie pełnej funkcjonalności).

Deprovisioning (offboarding) operatora generuje symetryczny łańcuch: żądanie dezaktywacji (requestor ID, powód, ticket reference), zatwierdzenie (approver ID, timestamp — dual-approval dla natychmiastowego offboardingu), rewokacja sesji (session kill timestamp, potwierdzenie rozłączenia), rewokacja MFA (device unregister, timestamp), rewokacja VPN (certificate revoke, CRL update timestamp), zniszczenie środowiska (namespace delete, workload destroy, storage wipe — kryptograficznie), archiwizacja logów (potwierdzenie, że logi operatora przeniesione do archiwum retencyjnego), dowód usunięcia (evidence of destroy — kryptograficzny dowód, że dane workloadowe nie istnieją).

Dla każdego certyfikatu: emisja (CA, serial, subject, validity, purpose, requestor), odnowienie (old serial → new serial, reason), rewokacja (reason, CRL/OCSP update, timestamp), wygaśnięcie (automatic audit record at expiry time).

Dla każdego tenanta: utworzenie, konfiguracja (tier, region, limity), zmiany konfiguracji (diff before/after), dezaktywacja, archiwizacja, zniszczenie z dowodem.

Raporty provisioningu: system musi umożliwiać generowanie raportu „pełny cykl życia obiektu X” — chronologiczna lista wszystkich zdarzeń dotyczących danego operatora/tenant/certyfikatu, eksportowalna w formacie PDF z podpisem cyfrowym potwierdzającym autentyczność eksportu.

23.5 Audytowalność zmian polityk

Status: [N] Normatywny Odbiorca: Compliance | SOC | Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 17.8, 18.5, 18.13, 23.3

Polityki bezpieczeństwa platformy SYLION — reguły definiujące kto, do czego, w jakich warunkach ma dostęp — stanowią krytyczny element kontrolny. Każda zmiana polityki musi być w pełni audytowalna, odwracalna i weryfikowalna. System zarządzania politykami musi implementować wzorzec analogiczny do kontroli wersji kodu (git-like), zapewniając pełną historię zmian.

Rekord zmiany polityki musi zawierać: identyfikator polityki (policy ID, wersja przed i po), diff (różnica w formacie before/after, czytelna dla człowieka i parsowalna maszynowo), autor zmiany (administrator ID, rola), zatwierdzający (approver ID — dual-approval obowiązkowy dla polityk Zone 3+), uzasadnienie (tekst, ticket reference), timestamp (moment zatwierdzenia, moment wdrożenia — mogą się różnić, wynik testów (ID test suite, pass/fail, pokrycie), moment aktywacji (deployment timestamp — kiedy polityka zaczęła obowiązywać), rollback info (czy zmiana została wycofana, kiedy, przez kogo).

Każda zmiana polityki musi przejść przez pipeline: draft → review → test → approve → deploy → verify. Na każdym etapie generowany jest rekord audytowy. Pominiecie etapu (np. deploy bez test) musi być technicznie niemożliwe w normalnym trybie; w trybie break-glass możliwe, ale z eskalacją i automatycznym alertem.

Testy polityk: każda polityka musi posiadać zdefiniowane test cases (minimum: jeden positive case — dostęp przyznany zgodnie z intencją, jeden negative case — dostęp odmówiony zgodnie z intencją). Testy wykonywane automatycznie przed deployment. Wynik testów jest częścią rekordu audytowego.

Wersjonowanie: system musi przechowywać pełną historię wersji każdej polityki (minimum 100 wersji wstecz lub 2 lata). Rollback do dowolnej poprzedniej wersji musi być możliwy w <5 minut (z zachowaniem pełnego pipeline approval dla rollback — rollback to też zmiana).

Polityki krytyczne (dotyczące Zone 3, G1/G2 rules, IAM root policies) muszą posiadać dodatkowe zabezpieczenie: zmiana wymaga zatwierdzenia trzech osób (triple approval), okres karencji 24 godziny przed aktywacją (chyba że break-glass), automatyczne powiadomienie CISO tenanta i SYLION Security Team.

23.6 Audytowalność eksportu danych

Status: [N] Normatywny Odbiorca: Compliance | SOC | Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 18.10, 20.4, 23.2

Eksport danych z Zone 3 — każdy plik opuszczający izolowane środowisko operatora i trafiający do terminala lub systemu zewnętrznego — stanowi potencjalny wektor eksfiltracji danych i podlega najsurowszym wymaganiom audytowalności. Ślad audytowy eksportu jest podstawowym narzędziem śledczym w przypadku podejrzenia wycieku danych.

Każdy eksport pliku generuje następujący rekord audytowy: operator ID (kto zainicjował eksport), workload źródłowy (env-office, env-browser, env-crm — z którego workloadu pochodzi plik), typ pliku (MIME type, rozszerzenie), rozmiar pliku (przed i po CDR), hash pliku (SHA-256 oryginału, SHA-256 po CDR — pozwalają na jednoznaczną identyfikację pliku), timestamp (moment żądania, moment CDR, moment dostarczenia do terminala), cel eksportu (terminal ID, jeśli eksport do innego systemu — system ID), decyzja polityki (ID polityki, wersja, wynik: ALLOW/DENY/QUARANTINE), metadane CDR (jakie transformacje zastosowano: metadata stripping, macro removal, format conversion).

Eksporty zablokowane (DENY) generują identyczny rekord jak eksporty dozwolone — z informacją o przyczynie blokady. Zablokowane eksporty są cennym źródłem intelligence o próbach naruszeń.

Eksporty do kwarantanny (QUARANTINE — plik wymaga manualnego review) generują dodatkowy rekord: reviewer ID, decyzja manualna (release/destroy), timestamp decyzji, uzasadnienie.

Korelacja eksportów: system musi umożliwiać zapytania typu: „pokaż wszystkie eksporty operatora X w ostatnim miesiącu”, „pokaż wszystkie eksporty plików > 10 MB z env-crm”, „pokaż operatorów z największą liczbą eksportów w tygodniu” (anomaly detection). Zapytania te muszą być realizowane w <10 sekund dla zakresu 30 dni.

Alerty eksportowe: automatyczny alert generowany przy: eksporcie powyżej progu rozmiaru (konfigurowalny, domyślnie 50 MB), eksporcie powyżej progu liczby (konfigurowalny, domyślnie 20 plików/dzień), eksporcie o nietypowej porze (poza standardowymi godzinami pracy operatora), eksporcie z workloadu, z którego operator normalnie nie eksportuje (behavioral baseline deviation).

Dashboard eksportów: panel administracyjny musi zawierać dedykowany widok aktywności eksportowej — per operator, per workload, per tenant, z trendami, anomaliami i możliwością drill-down do pojedynczego eksportu.

23.7 Audytowalność incydentów

Status: [N] Normatywny Odbiorca: Compliance | SOC | Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.8, 18.14, 20.12, 21.1–21.10

Każdy incydent bezpieczeństwa — od wykrycia do zamknięcia — musi generować kompletny, chronologiczny ślad audytowy umożliwiający rekonstrukcję zdarzeń, ocenę skuteczności reakcji i wyciągnięcie wniosków. Audytowalność incydentów jest kluczowa zarówno dla wewnętrznych procesów doskonalenia, jak i dla spełnienia wymogów regulacyjnych (GDPR art. 33 — notyfikacja naruszenia w 72h, NIS2 — raportowanie incydentów).

Ślad audytowy incydentu musi obejmować: detekcja (źródło alertu — automatyczne/manualne, timestamp, severity, opis, indicator of compromise), triage (analyst ID, timestamp rozpoczęcia, wstępna klasyfikacja — P1/P2/P3/P4, decyzja o eskalacji), containment (akcje podjęte — session kill, environment freeze, network isolation, timestamp każdej akcji, operator wykonujący), investigation (artefakty zebrane — logi, snapshoty, memory dumps, łańcuch custody dla każdego artefaktu — kto zebrał, kiedy, hash, gdzie przechowywany), eradication (root cause — opis techniczny, actions taken — patch, rebuild, policy change, weryfikacja — potwierdzenie, że zagrożenie wyeliminowane), recovery (services restored — lista, timestamp, verification — potwierdzenie pełnej funkcjonalności), post-incident (lessons learned — dokument, remediation actions — lista z terminami i odpowiedzialnymi, follow-up — weryfikacja implementacji remediation).

Łańcuch custody (chain of custody) dla dowodów forensics musi gwarantować: autentyczność (hash każdego artefaktu obliczony w momencie zebrania), integralność (artefakt przechowywany w WORM storage, hash weryfikowany przed każdym dostępem), dostępność (artefakt dostępny przez okres retencji), ograniczony dostęp (lista osób z dostępem do artefaktu, każdy dostęp logowany).

Timeline reconstruction: system musi umożliwiać automatyczne generowanie chronologicznej osi czasu incydentu na podstawie danych z Zone 4 — korelacja zdarzeń z różnych źródeł (G2 decisions, session events, network logs, workload events) w jednej spójnej osi czasu z rozdzielczością do milisekund.

Raportowanie incydentów: system musi wspierać automatyczne generowanie szablonu raportu incydentu (pre-filled z danych Zone 4), w formatach wymaganych przez regulatorów (GDPR breach notification, NIS2 significant incident report, wewnętrzny post-mortem).

23.8 Audytowalność raportowania zgodności

Status: [N] Normatywny Odbiorca: Compliance | Zarząd | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 17.8, 17.9, 23.1–23.7

Platforma SYLION musi umożliwiać zautomatyzowane generowanie pakietów dowodowych (evidence packages) na potrzeby audytów zgodności, certyfikacji i przeglądów regulacyjnych. Raportowanie zgodności nie jest jednorazowym wysiłkiem — musi być continuous compliance, gdzie dowody są zbierane na bieżąco i gotowe do prezentacji w dowolnym momencie.

System musi wspierać generowanie pakietów dowodowych dla następujących frameworków i standardów: GDPR (art. 25 — privacy by design, art. 30 — rejestr przetwarzania, art. 32 — zabezpieczenia techniczne, art. 33 — notyfikacja naruszeń, art. 35 — DPIA), ISO 27001 (Annex A controls — mapowanie kontroli SYLION na wymagania ISO), SOC 2 Type II (Trust Service Criteria — Security, Availability, Confidentiality), NIS2 (wymagania dla podmiotów kluczowych — zarządzanie ryzykiem, raportowanie incydentów), Common Criteria (dla ścieżki certyfikacji STATE/SOVEREIGN — Security Target, TOE description).

Każdy pakiet dowodowy musi zawierać: opis kontroli (co platforma robi, by spełnić wymaganie), dowód implementacji (konfiguracja, kod, polityka — automatycznie wyeksportowane z systemu), dowód działania (logi, metryki, wyniki testów za okres audytowy), dowód przeglądu (kto, kiedy, wynik — recertyfikacja kontroli), odchylenia (wykryte niezgodności, plan naprawczy, status realizacji).

Automatyzacja raportowania: system musi umożliwiać zdefiniowanie „compliance profile” (zestaw kontroli dla danego frameworka), automatyczne zbieranie dowodów z Zone 4 i management plane, automatyczną walidację kompletności (czy wszystkie kontrole mają aktualne dowody), generowanie raportu w formacie PDF z podpisem cyfrowym i znacznikiem czasu.

Dashboard zgodności: panel administracyjny musi zawierać widok „compliance posture” — wizualizację statusu zgodności per framework (zielony/żółty/czerwony per kontrola), z możliwością drill-down do szczegółów każdej kontroli, historii zmian i dowodów.

Audit trail samego raportowania: każde generowanie pakietu dowodowego, każdy dostęp do raportu zgodności, każda zmiana compliance profile muszą być logowane. To zamyka pętlę — audyt audytu gwarantuje, że sam proces raportowania jest godny zaufania.

Częstotliwość: compliance posture musi być aktualizowany automatycznie co 24 godziny. Pełny pakiet dowodowy musi być generowalny on-demand w <15 minut. Przegląd kontroli musi odbywać się minimum raz na kwartał (automatyczne przypomnienie do wyznaczonych osób).

Koniec Części III — Rozdziały 17–23 # CZĘŚĆ IV — ARCHITEKTURA KONTEKSTOWA I OPIS SYSTEMU

CZĘŚĆ IV — ARCHITEKTURA KONTEKSTOWA

Rozdział 24. Cele systemu i kluczowe funkcje

24.1 Cele systemowe

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 3.1, 5.2, 17.1, 25.1, 26.1

Platforma SYLION realizuje nadrzędny cel systemowy: zapewnienie bezpiecznej, suwerennej i audytowalnej przestrzeni komunikacji oraz pracy zdalnej dla organizacji wymagających ochrony na poziomie instytucji państwowych, służb specjalnych, infrastruktury krytycznej i korporacji o podwyższonym profilu ryzyka. Cel ten jest dekomponowany na pięć celów strategicznych, z których każdy przekłada się na mierzalne wymagania architektoniczne.

CEL-01: Bezpieczeństwo przez architekturę (Security by Architecture). System musi zapewniać ochronę nie przez nakładanie warstw zabezpieczeń na istniejącą infrastrukturę, lecz przez fundamentalny projekt architektoniczny, w którym bezpieczeństwo jest właściwością emergentną topologii, izolacji i modelu zaufania. Thin Client eliminuje dane na terminalu. Per-operator isolation eliminuje lateral movement. Immutable infrastructure eliminuje drift. Zero Trust eliminuje implicit trust. Każdy z tych mechanizmów redukuje klasę ataków — łącznie tworzą architekturę, w której kompromitacja jednego komponentu nie prowadzi do kompromitacji systemu.

CEL-02: Suwerenność operacyjna (Operational Sovereignty). Klient musi mieć możliwość pełnej kontroli nad swoimi danymi, kluczami kryptograficznymi, politykami dostępu i infrastrukturą obliczeniową — bez uzależnienia od operatora SYLION po zakończeniu wdrożenia. Suwerenność oznacza: dane nigdy nie opuszczają jurysdykcji klienta (w trybie sovereign), klucze root CA są generowane w HSM kontrolowanym przez klienta, polityki egzekwowane lokalnie. W trybie cloud managed klient deleguje operacje, ale zachowuje prawo do migracji i pełnego eksportu danych.

CEL-03: Audytowalność i zgodność (Auditability & Compliance). Każda operacja — sesja, decyzja polityki, transfer pliku, operacja administracyjna — musi generować niemodyfikowalny rekord audytowy. System musi być certyfikowalny wobec standardów: ISO 27001, SOC 2 Type II, CC EAL4+ (certifiable core), eIDAS (dla komponentów kryptograficznych w tierze STATE/SOVEREIGN). Certyfikowalność oznacza, że architektura, procesy i artefakty są zaprojektowane tak, aby audytor zewnętrzny mógł zweryfikować zgodność bez specjalnej wiedzy o wewnętrznych mechanizmach SYLION.

CEL-04: Skalowalność operacyjna (Operational Scalability). Platforma musi obsługiwać od pojedynczego operatora (proof of concept) do tysięcy operatorów w ramach jednego tenanta, bez zmiany architektury. Skalowanie musi być liniowe — dodanie kolejnych 100 operatorów nie wymaga zmiany topologii sieci, modelu izolacji ani architektury gateway. Target: 10 000 jednoczesnych sesji operatorów na klastrer.

CEL-05: Resilience i ciągłość działania (Resilience & Continuity). System musi przetrwać utratę dowolnego pojedynczego komponentu (single point of failure), dowolnego regionu chmury (w trybie multi-region) oraz dowolnego dostawcy infrastruktury (vendor independence). Czas odtworzenia środowiska operatora z czystego stanu: poniżej 30 minut. Czas odtworzenia pełnej platformy z DR: poniżej 4 godzin (STANDARD), poniżej 1 godziny (STATE/SOVEREIGN).

24.2 Funkcje podstawowe

Status: [N] Normatywny Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 18.1, 26.1, 27.5, 28.1

Funkcje podstawowe (baseline) stanowią minimalny zestaw funkcjonalności dostarczany w każdym wdrożeniu SYLION, niezależnie od wybranego tieru. Usunięcie dowolnej funkcji podstawowej oznacza, że wdrożenie nie spełnia wymagań baseline i nie może być prezentowane jako „SYLION-compliant”.

FN-B01: Bezpieczna sesja zdalna (Secure Remote Session). Operator łączy się z terminalem (Pixel/GrapheneOS lub zarządzany laptop) poprzez tunel IPsec IKEv2 do G1, przechodzi autoryzację w G2 i uzyskuje sesję zdalną do swoich workloadów w Zone 3. Sesja obejmuje pixel streaming (wyświetlanie treści), audio input/output (mikrofon/głośnik), input użytkownika (dotyk/klawiatura/mysz) oraz kontrolowany clipboard. Sesja jest utrzymywana przez session broker, który monitoruje heartbeat, timeout i device posture w trybie ciągłym. Session broker musi reagować na zmianę statusu urządzenia w czasie poniżej 30 sekund — jeśli device posture spadnie poniżej progu, sesja jest terminowana.

FN-B02: Komunikacja Matrix (Matrix Communication). Każdy operator otrzymuje workload env-matrix zawierający klienta Matrix (Element lub kompatybilny fork) połączony z dedykowanym homeserverem Matrix w Zone 3 tenanta. Komunikacja obejmuje: wiadomości tekstowe (szyfrowane end-to-end, Olm/Megolm), przesyłanie plików (przez pipeline CDR), rozmowy głosowe i wideo (VoIP przez Jitsi/LiveKit w Zone 3), pokoje (rooms) z kontrolą dostępu. Federacja Matrix jest domyślnie ograniczona — dozwolona tylko z jawnie zaaprobowanymi domenami w konfiguracji tenanta.

FN-B03: Przeglądarka internetowa (Web Browser). Workload env-browser zapewnia przeglądarkę (Chromium-based) uruchomioną w microVM. Ruch wychodzący przechodzi przez egress proxy z filtrowaniem URL (allowlist/denylist), inspekcją TLS (opcjonalnie, per policy) i logowaniem dostępu. Przeglądarka nie ma dostępu do sieci wewnętrznej SYLION — widzi tylko internet przez kontrolowany egress. Przeglądarka jest efemeryczna — stan (cookies, history, cache) jest domyślnie kasowany przy zamknięciu sesji.

FN-B04: Transfer plików przez CDR (File Transfer via CDR). Każdy plik wchodzący do Zone 3 musi przejść przez pipeline CDR: upload do staging area w Zone 4, analiza w efemerycznej microVM CDR, rekonstrukcja (usunięcie aktywnych treści, metadanych, makr), dostarczenie do workloadu żądającego. Pliki wychodzące z Zone 3 przechodzą inspekcję DLP (Data Loss Prevention) — klasyfikacja treści, blokowanie eksportu danych wrażliwych, audit trail.

FN-B05: Zarządzanie tożsamością i dostępem (IAM). Każdy operator posiada tożsamość w systemie IAM SYLION (Keycloak), uwierzytelnianą przez FIDO2 (wymagane dla STATE/SOVEREIGN, silnie rekomendowane dla PRO/STANDARD) lub OIDC z zewnętrznym IdP. Autoryzacja opiera się na modelu RBAC (Role-Based Access Control) z rozszerzeniami ABAC (Attribute-Based) — role definiują bazowe uprawnienia, atrybuty (czas, lokalizacja, device posture) modyfikują decyzję.

FN-B06: Logging i audyt (Logging & Audit). Każde zdarzenie bezpieczeństwa generuje rekord w formacie ustrukturyzowanym (JSON), dostarczany do Zone 4 SIEM w czasie poniżej 60 sekund. Rekordy są niemodyfikowalne (append-only log store), przechowywane minimum 12 miesięcy (STANDARD) lub 7 lat (STATE/SOVEREIGN).

FN-B07: Immutable Infrastructure. Cała infrastruktura jest definiowana jako kod (Terraform + Ansible). Żaden komponent produkcyjny nie jest modyfikowany in-place — zmiany wymagają nowego buildu i wdrożenia. Dryft konfiguracyjny jest wykrywany automatycznie i traktowany jako incydent bezpieczeństwa.

24.3 Funkcje rozszerzone

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 17.5, 18.6, 24.2, 27.6, 28.2

Funkcje rozszerzone wykraczają poza baseline i są dostępne w tierach PRO oraz STATE/SOVEREIGN. Ich aktywacja nie wymaga zmian w architekturze core — są realizowane jako dodatkowe moduły, workloady lub konfiguracje w istniejącej infrastrukturze.

FN-E01: Workload CRM (env-crm). Dedykowany workload microVM z aplikacją CRM (SuiteCRM, Odoo lub custom). Workload jest izolowany od pozostałych (brak lateral communication z env-matrix czy env-browser). Dane CRM przechowywane w encrypted volume per operator. Eksport danych z CRM przechodzi przez pipeline CDR (w kierunku outbound) z inspekcją DLP.

FN-E02: Workload Office (env-office). Dedykowany workload z pakietem biurowym (LibreOffice lub kompatybilny) do pracy z dokumentami OOXML i ODF. Workload zapewnia pełną edycję offline (w ramach sesji), współdzielenie dokumentów między operatorami tego samego tenanta (przez kontrolowany share w Zone 3), wersjonowanie i automatyczne backupy. Pliki importowane z zewnątrz przechodzą CDR. Pliki eksportowane przechodzą DLP.

FN-E03: Signal jako workload kompatybilności (env-signal). Workload w izolowanej microVM z klientem Signal. Signal jest traktowany jako zewnętrzna usługa komunikacyjna — ruch Signal przechodzi przez dedykowany egress (oddzielny od egress przeglądarki), nie łączy się z infrastrukturą Matrix, nie uczestniczy w wewnętrznych pokojach komunikacyjnych. Funkcja przeznaczona wyłącznie dla komunikacji z podmiotami zewnętrznymi, które nie używają Matrix.

FN-E04: Integracja z zewnętrznym IdP. Federacja tożsamości z IdP klienta (Azure AD, Okta, Google Workspace, ADFS, Ping Identity). Operator uwierzytelnia się wobec IdP klienta, SYLION otrzymuje token OIDC/SAML. Konfiguracja per tenant. Backchannel logout wymagany.

FN-E05: Eksport SIEM. Eksport zdarzeń do zewnętrznego SIEM klienta w formatach CEF, JSON-over-syslog, Splunk HEC, Azure Sentinel, QRadar. Konfigurowalny per tenant i per event category. Bufor retransmisji 72h.

FN-E06: API zarządzania (Management API). REST API do automatyzacji lifecycle operatora: provisioning, konfiguracja polityk, rewokacja, monitoring statusu, eksport raportów. OAuth 2.0 + mTLS. Rate limiting per tenant. OpenAPI 3.1 spec.

FN-E07: Multi-region DR. Replikacja konfiguracji (nie danych operacyjnych) do secondary region. Automatyczny failover session brokera. RTO poniżej 1h. Konfiguracja per tenant — klient wybiera region primary i secondary.

FN-E08: Zaawansowane polityki ABAC/PBAC. Rozszerzony model autoryzacji: polityki definiowane w OPA (Open Policy Agent) uwzględniające atrybuty kontekstowe (czas, lokalizacja, risk score, device posture score, classification label). Polityki wersjonowane, z pełnym audit trail zmian.

24.4 Funkcje premium i sovereign

Status: [N] Normatywny (dla tieru STATE/SOVEREIGN) Odbiorca: Zarząd | Architekt | Compliance | Klient Wpływ na baseline: Krytyczny (w ramach tieru) Powiązane rozdziały: 5.4, 17.3, 26.7, 26.8, 28.3

Funkcje premium i sovereign są wymagane normatywnie dla tieru STATE/SOVEREIGN i stanowią rozszerzenie baseline o mechanizmy dedykowane środowiskom o najwyższym profilu bezpieczeństwa: instytucje państwowe, infrastruktura krytyczna, operacje dyplomatyczne, służby specjalne.

FN-S01: Confidential Computing (AMD SEV-SNP / Intel TDX). Wszystkie workloady Zone 3 w tierze STATE/SOVEREIGN muszą działać w Trusted Execution Environment z aktywną ochroną pamięci operacyjnej. Technologie: AMD SEV-SNP (Secure Encrypted Virtualization — Secure Nested Paging) lub Intel TDX (Trust Domain Extensions). Gwarancja: operator infrastruktury chmurowej (hypervisor admin) nie ma dostępu do danych w pamięci workloadów. Attestation: każdy boot microVM generuje raport attestation weryfikowany przez G2 przed dopuszczeniem ruchu do workloadu. Attestation flow: microVM → hardware root of trust → attestation report → G2 verification → session allow/deny. Raport attestation zawiera measurement łańcucha bootowego (firmware, kernel, rootfs) — niezgodność z expected measurement powoduje odmowę sesji.

FN-S02: Dedykowany HSM (FIPS 140-3 Level 3). Tier STATE/SOVEREIGN wymaga dedykowanego Hardware Security Module: on-premise (nCIPHER nShield, Thales Luna, Utimaco) lub cloud-hosted (AWS CloudHSM, Azure Dedicated HSM) pod wyłączną kontrolą klienta. HSM przechowuje: root CA key (nigdy nie eksportowany), intermediate CA keys, klucze podpisujące polityki. Operacje kryptograficzne: generowanie certyfikatów, podpisywanie polityk, generowanie kluczy sesji — wykonywane wewnątrz HSM boundary, bez eksportu materiału kluczowego. PQC readiness: HSM musi obsługiwać algorytmy post-kwantowe (ML-KEM/Kyber, ML-DSA/Dilithium) — aktualnie jako opcja, planowane jako wymaganie od Q1 2027.

FN-S03: Suwerenna infrastruktura (Sovereign Infrastructure). Pełna platforma SYLION wdrożona na infrastrukturze kontrolowanej przez klienta: on-premise datacenter lub dedykowane konto w chmurze publicznej w jurysdykcji klienta. Brak zależności od operatora SYLION po zakończeniu wdrożenia (z wyjątkiem opcjonalnych: wsparcie, aktualizacje). Klient posiada pełną kontrolę nad: kluczami kryptograficznymi, politykami, danymi, kodem infrastrukturalnym (IaC), pipeline'ami CI/CD.

FN-S04: Post-Quantum Cryptography (PQC) Transition. Warstwa transportowa (IPsec IKEv2) musi wspierać hybrydowy key exchange: klasyczny (ECDH) + post-kwantowy (ML-KEM/Kyber-768). Certyfikaty: hybrid X.509 (ECDSA + ML-DSA). HSM: PQC-capable. Timeline: PQC-ready (opcjonalnie) od Q3 2026; PQC-mandatory dla nowych wdrożeń STATE/SOVEREIGN od Q1 2027; PQC-only (bez klasycznych algorytmów) — target 2030, zależny od standardów NIST/CNSA 2.0.

FN-S05: FIDO2 wymagane (FIDO2 Mandatory). Każdy operator w tierze STATE/SOVEREIGN musi używać sprzętowego klucza FIDO2 (YubiKey 5 NFC, Titan Security Key lub równoważnego) jako drugiego czynnika uwierzytelniania. Passwordless FIDO2 (resident credential) jest rekomendowaną konfiguracją. Backup credential: wymagane posiadanie minimum dwóch kluczy FIDO2 per operator (primary + recovery).

FN-S06: Pełna klasyfikacja danych (Full Data Classification). Wszystkie dane w Zone 3 i Zone 4 muszą posiadać etykietę klasyfikacji: UNRESTRICTED, INTERNAL, CONFIDENTIAL, SECRET, TOP SECRET. Etykiety są egzekwowane przez Policy Engine: operator z clearance CONFIDENTIAL nie może otworzyć dokumentu SECRET. Etykiety propagowane automatycznie: dokument utworzony w sesji z etykietą CONFIDENTIAL dziedziczy etykietę.

FN-S07: Wzmocniony audyt (Enhanced Audit). Rozszerzony logging: nagrywanie sesji (screen recording, opcjonalnie), pełny log keystroke (opcjonalnie, wymaga jawnej zgody operatora), retention 7+ lat, tamper-evident log chain (hash chain lub blockchain-anchored timestamps).

24.5 Funkcje eksperymentalne [E]

Status: [E] Eksperymentalny Odbiorca: Architekt | Dev | Zarząd Wpływ na baseline: Niski (nie wchodzi do baseline) Powiązane rozdziały: 24.7, 26.12, 29.1

Funkcje eksperymentalne są w fazie badań, prototypowania lub ograniczonego pilotażu. Nie wchodzą do baseline, nie podlegają certyfikacji, mogą zostać porzucone bez wpływu na architekturę core. Aktywacja funkcji eksperymentalnej wymaga jawnej flagi feature-flag i jest logowana jako zdarzenie administracyjne.

FN-X01: AI-assisted Security Analysis. Integracja modelu językowego (LLM) hostowanego w Zone 4 do analizy zdarzeń bezpieczeństwa: korelacja alertów, sugestie triage, generowanie podsumowań incydentów. LLM nie ma dostępu do treści komunikacji operatorów — otrzymuje wyłącznie metadane zdarzeń (timestamps, event types, IP addresses, decision outcomes). Model hostowany lokalnie (Llama, Mistral lub równoważny), bez ruchu do zewnętrznych API. Status: prototyp, planowany pilotaż Q4 2026. Ryzyko: halucynacje modelu mogą prowadzić do fałszywych korelacji — output LLM traktowany wyłącznie jako sugestia dla analityka SOC, nigdy jako automatyczna decyzja.

FN-X02: Automated Threat Hunting. Rozszerzenie FN-X01: automatyczne generowanie hypotheses threat hunting na podstawie MITRE ATT&CK i bieżącej telemetrii. System proponuje scenariusze hunting, analityk SOC akceptuje lub odrzuca, platforma wykonuje zapytania do SIEM i prezentuje wyniki. Status: badania, bez prototypu.

FN-X03: Decentralized Identity (DID/VC). Eksperymentalna integracja z protokołami tożsamości zdecentralizowanej (W3C DID, Verifiable Credentials). Cel: operator może przedstawić credential (np. poświadczenie bezpieczeństwa, certyfikat kompetencji) bez ujawniania pełnej tożsamości. Potential use case: międzyorganizacyjna komunikacja, gdzie operator A potwierdza „posiadam clearance SECRET” bez ujawniania imienia, nazwiska, organizacji. Status: badania, uzależnione od dojrzałości ekosystemu DID. Ryzyko: niski poziom standaryzacji, brak powszechnie akceptowanych trust frameworków.

FN-X04: Mesh VPN dla deploymentów terenowych. Eksperymentalny wariant topologii sieciowej dla scenariuszy edge/field: zamiast centralnego G1/G2, terminale tworzą mesh (WireGuard lub Noise protocol — wyłącznie dla mesh overlay, nie zastępuje IPsec IKEv2 na transport główny). Cel: resilience w warunkach degradowanej łączności. Status: koncepcja, wymaga analizy bezpieczeństwa. Ryzyko: poszerzenie attack surface, trudności z centralnym zarządzaniem politykami.

FN-X05: Hardware Token Integration. Integracja z dedykowanymi tokenami kryptograficznymi (smart card, CAC/PIV) jako alternatywa/uzupełnienie FIDO2. Cel: kompatybilność z istniejącą infrastrukturą PKI instytucji rządowych. Status: prototyp planowany Q2 2027. Ryzyko: różnorodność standardów (PKCS#11 vs. PIV vs. OpenPGP card) komplikuje implementację.

24.6 Funkcje wyłączone z baseline

Status: [N] Normatywny (wyłączenie jest normatywne) Odbiorca: Zarząd | Architekt | Compliance | Partner Wpływ na baseline: Krytyczny (brak = świadoma decyzja architektoniczna) Powiązane rozdziały: 26.6, 26.13, 29.2

Funkcje wyłączone z baseline to elementy, które zostały świadomie odrzucone z architektury SYLION na podstawie analizy ryzyka, niezgodności z modelem bezpieczeństwa lub niewystarczającej dojrzałości. Wyłączenie jest decyzją normatywną — oznacza, że dana funkcja nie może być zaimplementowana w ramach certyfikowalnego rdzenia bez ponownej analizy architektonicznej.

Incydent Signalgate (marzec 2025). W marcu 2025 ujawniono, że wysocy urzędnicy administracji USA omyłkowo udostępniłi informacje klasyfikowane SECRET/NOFORN w grupie Signal, do której przypadkowo dodano dziennikarza The Atlantic. Incydent potwierdził, że Signal nie jest narzędziem przeznaczonym do przetwarzania informacji niejawnych. Pentagon wydał memo (październik 2023, potwierdzone marzec 2025) zabraniające używania Signal do przetwarzania niepublicznych informacji DoD. Te zdarzenia wzmacniają decyzję architektoniczną SYLION o degradacji Signal z roli rdzenia do workloadu kompatybilności.

FN-OFF01: Signal jako rdzeń komunikacyjny. Signal jest traktowany wyłącznie jako workload kompatybilności (env-signal), nie jako podstawowy kanał komunikacyjny. Uzasadnienie: Signal wymaga rejestracji numerem telefonu (naruszenie prywatności operatorów), nie zapewnia kontrolowalnej federacji, nie obsługuje zaawansowanych polityk dostępu (pokoje, role, hierarchie), a jego infrastruktura jest kontrolowana przez podmiot trzeci (Signal Foundation). W SYLION rdzeń komunikacyjny to Matrix — własny homeserver, kontrolowana federacja, pełna audytowalność. Signal jest dopuszczalny wyłącznie do komunikacji z podmiotami zewnętrznymi, w izolowanej microVM z osobnym egress.

FN-OFF02: WireGuard jako transport VPN. WireGuard jest wyłączony z baseline. Uzasadnienie: WireGuard nie posiada walidacji FIPS 140-3, nie obsługuje CNSA 2.0 suite (wymagane dla STATE/SOVEREIGN), nie wspiera IKE negotiation (stałe klucze, brak dynamic rekeying w standardowym modelu), nie obsługuje hybrydowego PQC key exchange. Transport VPN w SYLION to wyłącznie IPsec IKEv2 (strongSwan, FIPS 140-3 validated). WireGuard może pojawić się wyłącznie w eksperymentalnym kontekście mesh VPN (FN-X04) — nigdy jako transport główny.

FN-OFF03: Pełny pulpit (Full Desktop) jako norma. Domyślny model wdrożenia to app-only publishing — operator widzi poszczególne workloady, nie pełny pulpit systemu operacyjnego. Pełny pulpit jest dostępny jako opcja [R] (rekomendowany dla zaawansowanych użytkowników), ale nie jest normatywny. Uzasadnienie: pełny pulpit zwiększa attack surface (operator widzi filesystem, system processes), utrudnia kontrolę clipboard i DLP, komplikuje audyty.

FN-OFF04: Anonimowość operatora. SYLION nie zapewnia anonimowości operatora. System jest zaprojektowany dla identyfikowalności — każdy operator posiada tożsamość, każda sesja jest audytowana, każda operacja przypisana do tożsamości. Twierdzenia o „anonimowym dostępie” są wykluczone z materiałów marketingowych i dokumentacji. Pseudonimowość (operator znany systemowi pod pseudonimem, a nie imieniem i nazwiskiem) jest dopuszczalna w wybranych scenariuszach — ale system zawsze zna tożsamość rzeczywistą na poziomie administracyjnym.

FN-OFF05: Tails OS na VPS. Koncepcja uruchomienia Tails OS jako systemu operacyjnego workloadu w VPS jest odrzucona. Uzasadnienie: Tails jest zaprojektowany jako system stacjonarny z amnezycznym storage — uruchomienie na VPS nie zapewnia korzyści (amnezja jest cechą lokalną, VPS zachowuje dane w hypervisor storage), a dodaje złożoność (Tails nie jest zoptymalizowany pod Firecracker/microVM, wymaga custom bootloadera). Workloady SYLION używają minimalnych obrazów Alpine/NixOS zoptymalizowanych pod Firecracker.

24.7 Funkcje autonomiczne [A]

Status: [A] Autonomiczny Odbiorca: Architekt | Dev | Infra Wpływ na baseline: Niski (niezależne od certyfikowalnego rdzenia) Powiązane rozdziały: 24.5, 26.12, 29.1

Funkcje autonomiczne działają poza certyfikowalnym rdzeniem SYLION — mogą być wdrażane, modyfikowane lub usuwane bez wpływu na certyfikację core. Ich architektura jest zdefiniowana, ale ewolucja nie podlega rygorom change management rdzenia. Funkcje autonomiczne muszą jednak przestrzegać granic izolacji — nie mogą komunikować się z rdzeniem inaczej niż przez zdefiniowane API w Zone 4.

FN-A01: Portal administracyjny (Admin Portal). Aplikacja webowa do zarządzania platformą: provisioning operatorów, konfiguracja polityk, monitoring statusu, raporty. Portal jest autonomiczny — jego frontend (React/Next.js) i backend (API w Go) działają w Zone 5, komunikują się z rdzeniem wyłącznie przez Management

API. Portal może być zastąpiony innym narzędziem (CLI, custom dashboard) bez wpływu na core. Bezpieczeństwo portalu: mTLS + OAuth 2.0, dostęp wyłącznie z bastionu lub przez VPN administracyjny, FIDO2 wymagane dla administratorów STATE/SOVEREIGN.

FN-A02: Monitoring i dashboardy (Monitoring Dashboards). Stack monitoringowy: Prometheus (metryki), Grafana (wizualizacja), Loki (logi aplikacyjne — nie security logs, które trafiają do SIEM). Stack działa w Zone 4, zbiera metryki z Zone 2–5. Dashboardy: health (dostępność komponentów), performance (latencja sesji, throughput CDR), capacity (zużycie zasobów per operator). Stack jest autonomiczny — może być wymieniony na inny (Datadog, Elastic) bez wpływu na core.

FN-A03: System ticketowy (Ticketing System). Opcjonalna integracja lub wbudowany system ticketowy dla SOC: automatyczne tworzenie ticketów z alertów SIEM, workflow eskalacji, SLA tracking. Autonomiczny — komunikacja z rdzeniem wyłącznie przez API i webhook.

FN-A04: Knowledge Base. Dokumentacja operatorska, procedury SOC, runbooki. Może być hostowana jako workload (wiki w Zone 4) lub zewnętrznie. Autonomiczna wobec rdzenia.

FN-A05: Backup i archiwizacja. System backupów konfiguracji (nie danych operacyjnych — workloady są efemeryczne). Narzędzia: Restic/Borg z encrypted storage. Autonomiczny moduł — interfejs z rdzeniem wyłącznie przez API (trigger backup, verify restore). Backup obejmuje: konfiguracje Terraform state, polityki OPA, konfiguracje Keycloak, certyfikaty (bez kluczy prywatnych HSM — te nie opuszczają HSM).

FN-A06: CI/CD Pipeline. Pipeline budowy obrazów, testów bezpieczeństwa i deploymentu. Narzędzia: GitLab CI lub GitHub Actions (self-hosted runner), Trivy (image scanning), Cosign (image signing). Pipeline autonomiczny — output (signed images) jest consumed przez rdzeń, ale sam pipeline nie jest częścią certyfikowalnego rdzenia. Pipeline musi jednak spełniać wymagania SLSA v1.2 Level 3 (provenance, hermetyczny build, audytowalność).

Rozdział 25. Granice systemu i diagram kontekstowy

25.1 Granice logiczne

Status: [N] Normatywny Odbiorca: Architekt | Compliance | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 5.1, 17.1, 24.1, 25.2, 25.3, 26.12

Granice logiczne systemu SYLION definiują, co jest „wewnątrz” systemu (pod kontrolą operatora SYLION lub klienta sovereign), a co jest „na zewnątrz” (poza kontrolą, traktowane jako niezaufane). Definicja granic jest fundamentalna dla modelu zagrożeń, zakresu certyfikacji i odpowiedzialności kontraktowej.

Granica wewnętrzna — certyfikowalny rdzeń (Certifiable Core). Obejmuje komponenty, których integralność i poprawność jest gwarantowana przez architekturę, procesy i (docelowo) certyfikację: Split Gateway (G1 + G2), Session Broker, Policy Engine (OPA), Firecracker orchestration, CDR engine, HSM integration, IPsec transport (strongSwan), IAM (Keycloak core), Log pipeline (collector → SIEM ingest), IaC (Terraform modules, Ansible roles). Certifiable core podlega pełnym rygorom change management: peer review, security review, automated testing, signed release, audit trail.

Granica wewnętrzna — moduły autonomiczne. Obejmuje komponenty wspierające, które działają poza certyfikowalnym rdzeniem, ale w ramach infrastruktury SYLION: Admin Portal, Monitoring stack, CI/CD pipeline, Backup system, Knowledge Base. Moduły autonomiczne podlegają ogólnym praktykom bezpieczeństwa (code review, vulnerability scanning), ale nie podlegają rygorom certyfikacji rdzenia.

Granica zewnętrzna — terminale operatorów (Zone 0). Terminale (Pixel/GrapheneOS, zarządzane laptopy) są zarządzane przez SYLION (profil MDM, konfiguracja VPN, FIDO2 enrollment), ale fizycznie znajdują się poza kontrolą infrastrukturalną. Terminal jest traktowany jako „semi-trusted”: zaufany na poziomie device posture (weryfikowany ciągłe), ale niezaufany na poziomie danych (brak danych aplikacyjnych na terminalu).

Granica zewnętrzna — infrastruktura chmurowa. Dostawca IaaS (Hetzner, OVH, AWS, Azure) jest traktowany jako niezaufany na poziomie danych — Confidential Computing (AMD SEV-SNP / Intel TDX) chroni dane w pamięci operacyjnej workloadów przed operatorem infrastruktury. Dostawca jest zaufany na poziomie dostępności (SLA) i fizycznego bezpieczeństwa (certyfikacja datacenter), ale nie na poziomie poufności danych.

Granica zewnętrzna — systemy klienta. IdP klienta (Azure AD, Okta), SIEM klienta, MDM klienta — systemy pod kontrolą klienta, z którymi SYLION integruje się przez zdefiniowane interfejsy. SYLION traktuje te systemy jako „conditionally trusted”: ufa ich twierdzeniom (np. assertion SAML), ale weryfikuje ich integralność (np. backchannel logout, token validation).

Granica zewnętrzna — internet. Ruch internetowy (egress przeglądarki, Signal egress) jest traktowany jako w pełni niezaufany. Przechodzi przez dedykowane punkty egress z filtrowaniem i logowaniem.

25.2 Granice sieciowe

Status: [N] Normatywny Odbiorca: Architekt | Infra | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 5.1, 6.1, 17.3, 25.1, 25.3, 29.4

Granice sieciowe SYLION są realizowane przez sześć stref bezpieczeństwa (Zone 0–5), z których każda posiada odrębną politykę ruchu, mechanizmy filtrowania i model zaufania. Granice sieciowe nie pokrywają się z granicami logicznymi — jedna strefa logiczna może obejmować wiele segmentów sieciowych.

Zone 0 → Zone 1 (Terminal → Access Network). Granica: fizyczne połączenie sieciowe (WiFi, LTE/5G, Ethernet). Mechanizm: tunel IPsec IKEv2 zestawiany przez klienta strongSwan na terminalu. Kill switch: cały ruch non-IPsec jest blokowany na terminalu (iptables/nftables rule set zarządzany przez profil MDM). Granica jest chroniona kryptograficznie — cały ruch jest szyfrowany w tunelu IPsec.

Zone 1 → Zone 2 (Access Network → Gateway). Granica: terminacja tunelu IPsec w G1. G1 deszyfruje ruch transportowy (warstwa L3/L4), przeprowadza inspekcję pakietów (firewall stateful, anti-DDoS), a następnie przekazuje ruch do G2 przez wewnętrzne połączenie (mutual TLS lub IPsec inter-gateway). Granica jest punktem demarkacji odpowiedzialności: ruch przed G1 jest w gestii terminala i sieci dostępowej; ruch po G1 jest w gestii infrastruktury SYLION.

Zone 2 → Zone 3 (Gateway → Operator Workloads). Granica: G2 routuje sesję do środowiska operatora na podstawie wyniku ewaluacji polityki. Ruch między G2 a workloadem przechodzi przez wirtualną sieć per-operator (VXLAN/VRF lub dedykowany network namespace). Granica jest punktem mikrosegmentacji — każdy operator ma odrębny segment sieciowy, brak ruchu lateral między operatorami.

Zone 3 → Zone 4 (Workloads → Shared Services). Granica: workloady mogą komunikować się z wybranymi usługami Zone 4 (CDR, API, backup) przez zdefiniowane punkty (service mesh sidecar lub eBPF-enforced policy). Lista dozwolonych usług jest definiowana per workload type (np. env-browser ma dostęp do egress proxy, nie ma dostępu do CDR; env-matrix ma dostęp do CDR, nie ma dostępu do egress proxy).

Zone 5 → Zone 2/3/4 (Management → Infrastructure). Granica: Zone 5 ma dostęp administracyjny do Zone 2, 3 i 4 — ale wyłącznie przez bastion host z FIDO2 i audit trail. Zone 5 jest nieosiągalna z Zone 0 i Zone 3 — nie istnieje ścieżka sieciowa z terminala operatora do management plane.

Ruch zabroniony (Forbidden Traffic). Zone 0 → Zone 3 (direct bypass of gateway), Zone 0 → Zone 5 (terminal to management), Zone 3 → Zone 5 (workload to management), Operator A Zone 3 → Operator B Zone 3 (lateral movement). Naruszenie tych granic generuje alert krytyczny w SIEM i automatyczną terminację sesji.

25.3 Granice zaufania

Status: [N] Normatywny Odbiorca: Architekt | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 5.1, 17.3, 25.1, 25.2, 26.1, 29.3

Model zaufania SYLION opiera się na zasadzie Zero Trust: żaden komponent nie jest domyślnie zaufany, każdy dostęp wymaga weryfikacji. Granice zaufania definiują, na jakich warunkach komponent A może ufać komponentowi B — i co się dzieje, gdy zaufanie zostaje naruszone.

Trust Boundary 1: Terminal → Gateway (TB-1). Terminal jest semi-trusted. Warunki zaufania: (1) certyfikat klienta IPsec jest ważny i nie został odwołany (CRL/OCSP check w G1), (2) device posture spełnia minimalne wymagania (wersja OS, integralność konfiguracji, status FIDO2 enrollment), (3) tożsamość operatora jest potwierdzona przez FIDO2/OIDC. Naruszenie dowolnego warunku: sesja odmówiona lub terminowana. Ciągła weryfikacja: device posture re-evaluated co 5 minut (configurable). Sesja terminowana w ciągu 30 sekund od wykrycia naruszenia.

Trust Boundary 2: G1 → G2 (TB-2). G1 jest trusted-but-limited. G1 widzi ruch L3/L4, ale nie widzi warstwy aplikacyjnej (nie posiada kluczy sesji aplikacyjnej). G2 ufa G1 w zakresie: poprawności deszyfrowania transportu, integralności pakietów (nie zostały zmodyfikowane). G2 nie ufa G1 w zakresie: tożsamości operatora (G2 weryfikuje samodzielnie), polityki dostępu (G2 podejmuje decyzję niezależnie od G1). Kompromitacja G1 oznacza: atakujący widzi ruch L3/L4 (zaszyfrowany na poziomie aplikacji), nie widzi treści sesji, nie może podszyć się pod operatora (nie posiada FIDO2 credential), nie może obejść polityki G2.

Trust Boundary 3: G2 → Workload (TB-3). G2 jest trusted w zakresie routingu i egzekucji polityki. Workload ufa G2, że sesja została autoryzowana poprawnie. G2 ufa workloadowi w zakresie: poprawności attestation (dla STATE/SOVEREIGN — measurement łańcucha boot musi zgadzać się z expected value). Kompromitacja G2 jest scenariuszem krytycznym — wymaga response plan obejmujący pełną rewokację sesji i revalidację tożsamości.

Trust Boundary 4: Workload → Shared Services (TB-4). Workload jest semi-trusted wobec usług Zone 4. Komunikacja uwierzytelniana per-service (mTLS per workload type). Workload nie może eskalować uprawnień w Zone 4 — service mesh/eBPF ogranicza dostępne usługi per workload type.

Trust Boundary 5: Management → Everything (TB-5). Zone 5 jest highest-trust — ale dostęp do Zone 5 jest najsilniej chronionym zasobem w systemie. Wymagania: bastion host, FIDO2, audit trail, principle of least privilege, break-glass z dwuosobową autoryzacją. Kompromitacja Zone 5 jest najpoważniejszym scenariuszem — response plan obejmuje pełny rebuild infrastruktury z IaC.

Trust boundary per operator. W ramach Zone 3 każdy operator stanowi odrębną trust boundary. Operator A nie może komunikować się z Operatorem B — sieciowo, kryptograficznie i na poziomie polityki. Nawet jeśli dwa środowiska operatorów działają na tym samym węźle fizycznym, izolacja jest gwarantowana przez: odrębne network namespace, odrębne klucze kryptograficzne, odrębne microVM (Firecracker), oraz Confidential Computing (w tierze STATE/SOVEREIGN — odrębne TEE per operator).

25.4 Interakcje z użytkownikami

Status: [N] Normatywny Odbiorca: Architekt | Dev | Klient | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 17.2, 24.2, 27.1, 27.4, 31.1

System SYLION definiuje cztery role użytkowników, z których każda ma odrębny model interakcji, interfejs i granice uprawnień. Interakcje użytkowników przechodzą wyłącznie przez zdefiniowane punkty wejścia — nie istnieje „tylne wejście” ani nieudokumentowany kanał.

Operator (Rola: OPERATOR). Podstawowy użytkownik platformy. Interakcja: terminal (Pixel/GrapheneOS lub laptop) → tunel IPsec → G1 → G2 → sesja zdalna do workloadów. Operator widzi wyłącznie swoje workloady (env-matrix, env-browser, env-office, env-crm, env-signal, env-voice) jako aplikacje lub okna — nie widzi infrastruktury, konfiguracji sieci, polityk. Operator nie ma dostępu do terminala linii poleceń systemu operacyjnego workloadu (w modelu app-only publishing). Operator może: komunikować się (Matrix, Signal, voice), przeglądać internet, pracować z dokumentami, transferować pliki (przez CDR). Operator nie może: zmieniać konfiguracji sieci, instalować oprogramowania, eksportować danych poza kontrolę DLP.

Administrator tenanta (Rola: TENANT_ADMIN). Zarządza operatorami i politykami w ramach swojego tenanta. Interakcja: portal administracyjny (Zone 5, przez VPN administracyjny) lub Management API. Administrator tenanta może: provisioning/offboarding operatorów, definiować polityki (RBAC role, ABAC rules), konfigurować integracje (IdP, SIEM), monitorować status operatorów i workloadów, generować raporty audytowe. Administrator tenanta nie może: modyfikować infrastruktury (sieć, gateway, HSM), dostępować workloadów innych tenantów, modyfikować kodu źródłowego.

Administrator platformy (Rola: PLATFORM_ADMIN). Zarządza infrastrukturą SYLION. Interakcja: bastion host (Zone 5) → IaC (Terraform/Ansible) → infrastruktura. Administrator platformy nie ma dostępu do treści sesji operatorów — widzi telemetrię (metryki, logi infrastrukturalne), ale nie treść komunikacji. W tierze STATE/SOVEREIGN administrator platformy jest klientem (lub wyznaczonym pełnomocnikiem klienta) — SYLION nie ma dostępu do infrastruktury. Administrator platformy może: wdrażać i aktualizować komponenty, zarządzać siecią (Zone 1–5), zarządzać HSM (ceremonie kluczowe), reagować na incydenty. Administrator platformy nie może: odczytywać treści sesji, modyfikować polityk tenanta (to rola TENANT_ADMIN), działać bez audit trail.

Audytory (Rola: AUDITOR). Dostęp read-only do logów, raportów i konfiguracji. Interakcja: portal audytowy (ograniczony widok Admin Portal) lub API z uprawnieniami read-only. Audytor może: przeglądać logi zdarzeń, pobierać raporty zgodności, weryfikować konfiguracje polityk. Audytor nie może: modyfikować konfiguracji, inicjować sesji, provisioning operatorów. Rola przeznaczona dla wewnętrznych audytorów klienta, audytorów zewnętrznych (ISO 27001, SOC 2) oraz regulatorów.

25.5 Interakcje z systemami zewnętrznymi

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 17.5, 24.3, 27.10, 31.8

SYLION komunikuje się z systemami zewnętrznymi wyłącznie przez zdefiniowane interfejsy w Zone 4 (data plane) lub Zone 5 (control plane). Każda interakcja zewnętrzna jest uwierzytelniana, szyfrowana i logowana.

EXT-01: External Identity Provider (IdP). Kierunek: SYLION ← IdP klienta. Protokoły: OIDC, SAML 2.0. Cel: federacja tożsamości — operator uwierzytelnia się wobec IdP klienta, SYLION otrzymuje token/assertion. Punkt integracji: Keycloak (Zone 5) jako identity broker. Bezpieczeństwo: backchannel logout (wymagany), PKCE (wymagany dla OIDC), signature validation (wymagany dla SAML). Ryzyko: kompromitacja IdP klienta umożliwia wystawienie fałszywego tokena — mitigacja: SYLION weryfikuje dodatkowe atrybuty (device posture, FIDO2) oprócz tokena IdP.

EXT-02: External SIEM. Kierunek: SYLION → SIEM klienta. Protokoły: syslog/TLS, Splunk HEC, Sentinel Data Connector, QRadar. Cel: eksport zdarzeń bezpieczeństwa. Punkt integracji: log exporter w Zone 4. Bezpieczeństwo: transport TLS 1.3, uwierzytelnianie certificate-based lub token-based, filtrowanie per tenant (klient widzi tylko swoje zdarzenia). Ryzyko: awaria SIEM klienta — mitigacja: bufor retransmisji 72h w Zone 4.

EXT-03: Signal Infrastructure. Kierunek: SYLION (env-signal) → Signal servers (internet). Cel: komunikacja z użytkownikami Signal. Punkt integracji: dedykowany egress w Zone 3 per workload env-signal. Ruch Signal przechodzi przez egress proxy — SYLION nie terminuje szyfrowania Signal (E2E encryption). Bezpieczeństwo: izolacja egress (Signal egress ≠ browser egress ≠ Matrix egress), logowanie metadanych (timestamps, rozmiar, ale nie treść).

EXT-04: Software Update Repositories. Kierunek: SYLION ← repozytoria (OS packages, container images). Cel: aktualizacje komponentów. Punkt integracji: pull-only z Zone 5 (CI/CD pipeline). Bezpieczeństwo: image signature verification (Cosign/Notary v2), checksum validation, pull only from allowlisted repositories. Ryzyko: supply chain attack — mitigacja: SLSA v1.2 Level 3 provenance, image pinning by digest.

EXT-05: Internet (Browser Egress). Kierunek: SYLION (env-browser) → internet. Cel: dostęp operatora do stron internetowych. Punkt integracji: egress proxy w Zone 3/4. Bezpieczeństwo: URL filtering (allowlist/denylist per policy), TLS inspection (opcjonalnie), logowanie URL, CDR dla pobieranych plików. Ryzyko: exfiltration via browser — mitigacja: DLP na egress, clipboard control, screen recording (opcjonalnie w STATE/SOVEREIGN).

EXT-06: NTP / Time Synchronization. Kierunek: SYLION ← NTP servers. Cel: synchronizacja czasu (krytyczna dla logów, certyfikatów, tokenów). Punkt integracji: dedicated NTP servers w Zone 4, synchronizowane z zewnętrznymi source (GPS, authenticated NTP). Bezpieczeństwo: NTS (Network Time Security, RFC 8915) lub authenticated NTP. Ryzyko: time-shift attack — mitigacja: monitoring drift, alert na odchylenia > 100ms.

25.6 Interakcje z dostawcami infrastruktury

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Infra | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 17.1, 24.1, 25.1, 28.1, 28.2, 28.3

Dostawcy infrastruktury dostarczają zasoby obliczeniowe, sieciowe i storage, na których działa SYLION. Relacja z dostawcą jest zdefiniowana kontraktowo i architektonicznie — SYLION minimalizuje zaufanie wobec dostawcy.

IaaS Providers (Hetzner, OVH, AWS, Azure, GCP). Dostawca zapewnia: serwery bare-metal lub VM, sieć (public IP, private networking), storage (block, object), connectivity (bandwidth, DDoS protection na poziomie sieci). SYLION traktuje dostawcę jako „untrusted compute provider” — dane w pamięci operacyjnej workloadów są chronione przez Confidential Computing (TEE) w tierze STATE/SOVEREIGN. Dostawca nie ma dostępu do kluczy kryptograficznych (przechowywane w HSM), treści sesji ani polityk. Interakcja z dostawcą: API dostawcy (provisioning serwerów) wywoływane wyłącznie z Zone 5 (IaC pipeline). Credential API dostawcy przechowywane w secrets manager (Vault/SOPS) z audit trail.

Colocation Providers (dla on-premise sovereign). Dostawca zapewnia: przestrzeń rack, zasilanie, chłodzenie, fizyczne bezpieczeństwo (kontrola dostępu, CCTV). Klient (lub SYLION) dostarcza: serwery, networking equipment, HSM. Interakcja: fizyczna instalacja hardware (jednorazowa), konserwacja fizyczna (planowana, z eskortą). Dostawca colocation nie ma dostępu logicznego do żadnego komponentu SYLION. Wymagania: certyfikacja Tier III+ datacenter, SSAE 18 / ISAE 3402 SOC 2 Type II.

HSM Vendors (Thales, Entrust/nCipher, Utimaco). Dostawca zapewnia: hardware (HSM appliance), firmware updates, wsparcie techniczne. HSM jest zarządzany wyłącznie przez klienta (lub administratora platformy) — vendor nie ma zdalnego dostępu. Firmware update: wyłącznie po weryfikacji podpisu vendor, z pełnym audit trail, w procedurze z dwuosobową autoryzacją. Interakcja: jednorazowa dostawa hardware + recurring firmware updates (signed, offline delivery dla STATE/SOVEREIGN).

DNS Providers. Dostawca zapewnia: autoritativ DNS dla domen SYLION. SYLION używa minimalnej ekspozycji DNS — publiczne rekordy ograniczone do G1 endpoints. Bezpieczeństwo: DNSSEC (wymagany), multi-provider DNS (redundancja), monitoring DNS hijacking.

Certificate Authorities (Let's Encrypt, DigiCert — dla certyfikatów publicznych). Dostawca zapewnia: certyfikaty TLS dla publicznych endpoints (G1). Certyfikaty wewnętrzne (mTLS między komponentami, certyfikaty operatorów) wydawane przez wewnętrzne CA (Keycloak/Vault PKI, backed by HSM) — nie przez zewnętrzne CA. Interakcja: ACME protocol (Let's Encrypt) lub API (DigiCert) z Zone 5.

25.7 Interakcje z partnerami

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Compliance Wpływ na baseline: Średni Powiązane rozdziały: 17.5, 24.3, 25.5, 27.10

Ekosystem partnerski SYLION obejmuje podmioty, które dostarczają komplementarne usługi, integracje lub uczestniczą w łańcuchu wartości. Interakcje z partnerami przechodzą przez zdefiniowane interfejsy i podlegają kontraktowej kontroli.

Partnerzy wdrożeniowi (Implementation Partners). Firmy realizujące wdrożenia SYLION u klientów końcowych. Interakcja: dostęp do dokumentacji technicznej (Knowledge Base), środowiska testowego (sandbox), Management API (w zakresie provisioning). Partner wdrożeniowy nie ma dostępu do środowisk produkcyjnych klientów — jego rola kończy się na handoff po zakończeniu wdrożenia. Partner podpisuje NDA i podlega security vettingowi (weryfikacja procedur bezpieczeństwa, szkolenie z architektury SYLION).

Partnerzy technologiczni (Technology Partners). Dostawcy komponentów zintegrowanych z SYLION: dostawcy CDR engine (np. Votiro, OPSWAT, Glasswall), dostawcy MDM (Intune, Jamf), dostawcy IdP (Okta, Ping Identity). Interakcja: API-to-API, zdefiniowane kontrakty danych (OpenAPI spec), SLA. Partner technologiczny dostarcza komponent jako usługę — SYLION integruje go przez wrapper w Zone 4 z pełnym audit trail. Bezpieczeństwo: mTLS, API key rotation, monitoring dostępności partnera (circuit breaker).

Partnerzy kanałowi (Channel Partners). Resellerzy SYLION. Interakcja: dostęp do portalu partnerskiego (licensing, provisioning przez API), materiały marketingowe, szkolenia. Partner kanałowy nie ma dostępu do infrastruktury ani danych klientów. Interakcja ograniczona do warstwy biznesowej (zamówienia, licencje, first-line support).

Partnerzy audytowi (Audit Partners). Firmy audytowe realizujące certyfikacje (ISO 27001, SOC 2, CC). Interakcja: dostęp read-only do dokumentacji, konfiguracji (sanitized), logów (sanitized — bez treści sesji). Rola AUDITOR w systemie z ograniczonymi uprawnieniami. Partner audytowy podpisuje NDA i otrzymuje access token z ograniczonym czasem ważności (time-limited, per engagement).

25.8 Diagram kontekstowy L0 (ASCII art — full system overview)

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Partner | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 25.1–25.7, 26.1, 27.1–27.12

Diagram L0 przedstawia SYLION jako „czarną skrzynkę” w kontekście wszystkich aktorów i systemów zewnętrznych. Strzałki oznaczają kierunek dominującego przepływu danych; większość interakcji jest dwukierunkowa (request/response), strzałka wskazuje inicjatora.

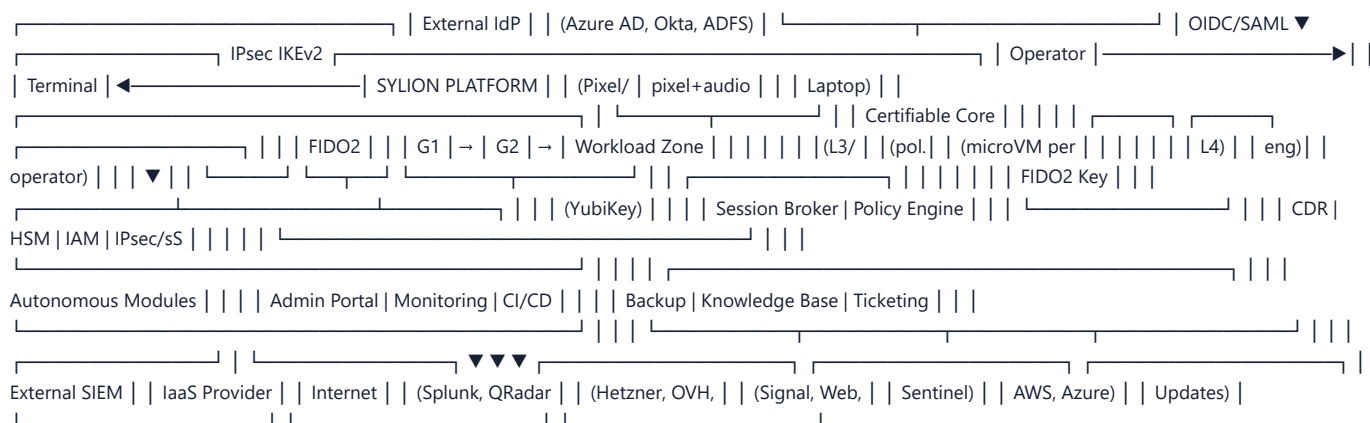
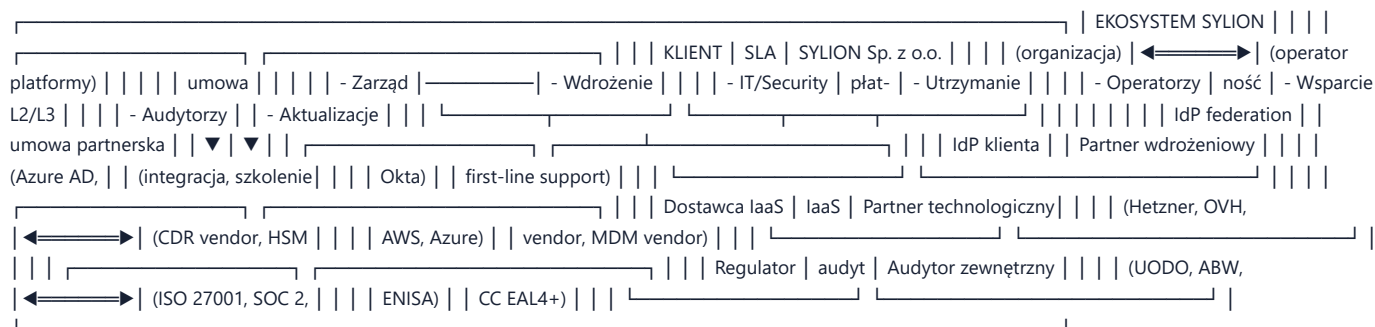


Diagram ilustruje kluczowe zasady: operator wchodzi wyłącznie przez IPsec → G1 → G2 → workloady. Systemy zewnętrzne (IdP, SIEM) komunikują się przez zdefiniowane interfejsy. Dostawca IaaS jest „pod” platformą — nie jest aktorem, a dostawcą zasobów. Internet jest dostępny wyłącznie przez kontrolowane punkty egress.

25.9 Diagram kontekstowy biznesowy

Status: [R] Rekomendowany Odbiorca: Zarząd | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 24.1, 25.4, 25.7, 28.1

Diagram biznesowy przedstawia SYLION z perspektywy aktorów biznesowych — bez szczegółów technicznych. Pokazuje, kto za co płaci, kto co dostarcza i jakie przepływy wartości istnieją.

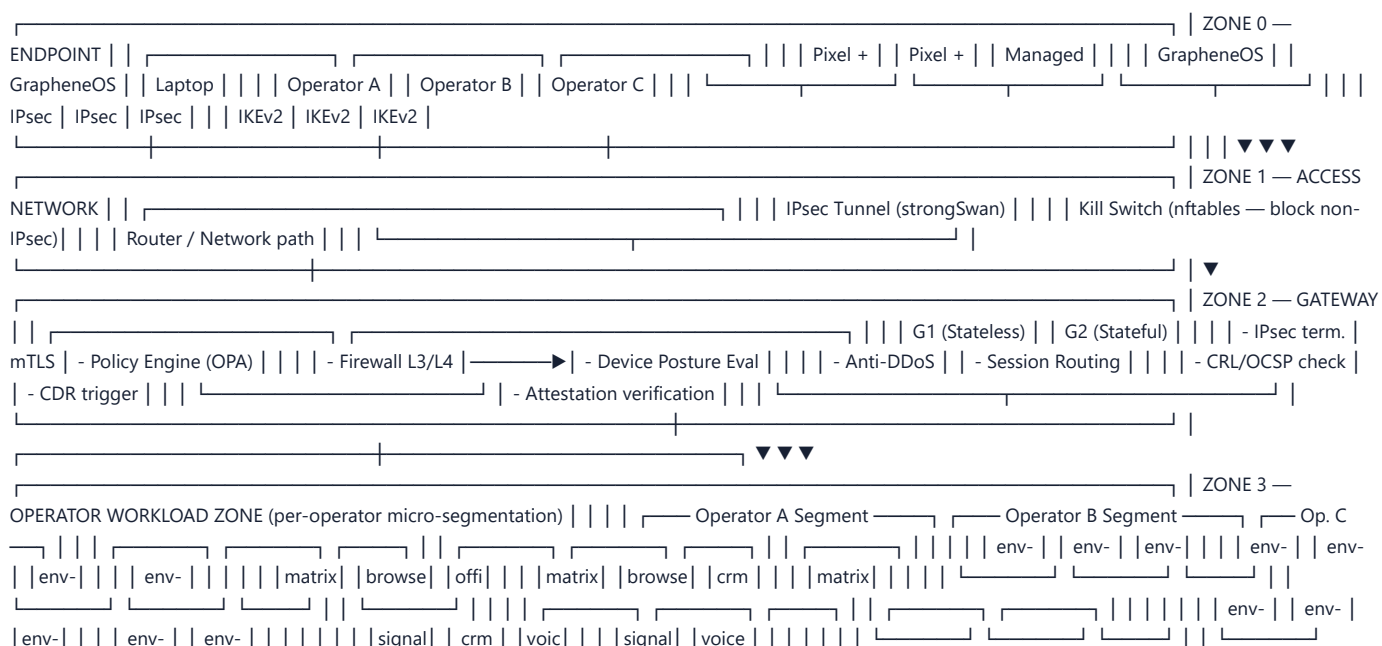


Kluczowe przepływy wartości: klient płaci za usługę (subskrypcja per operator per miesiąc), SYLION dostarcza bezpieczną platformę, partner wdrożeniowy realizuje integrację, partner technologiczny dostarcza komponenty (CDR, HSM), dostawca IaaS zapewnia zasoby, audytor weryfikuje zgodność. W modelu sovereign klient może wyeliminować SYLION z łańcucha operacyjnego (self-managed) — relacja ogranicza się do licencji i opcjonalnego wsparcia.

25.10 Diagram kontekstowy techniczny (ASCII art — zone topology)

Status: [N] Normatywny Odbiorca: Architekt | Infra | SOC | Dev Wpływ na baseline: Krytyczny Powiązane rozdziały: 5.1, 6.1, 25.2, 27.1–27.12, 29.4

Diagram techniczny prezentuje topologię stref bezpieczeństwa (Zone 0–5) z zaznaczonymi komponentami, kierunkami ruchu i punktami kontroli.



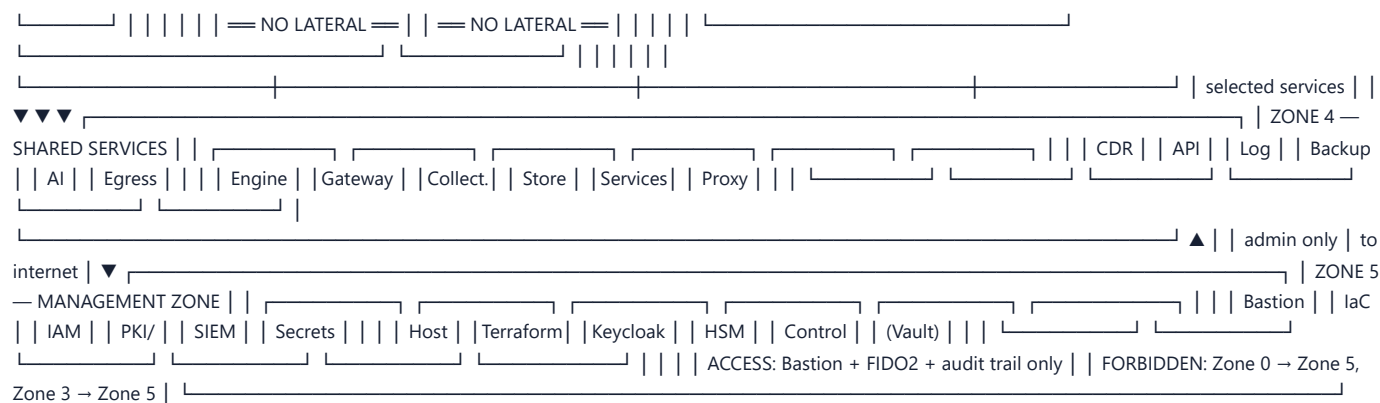


Diagram ten stanowi referencyjną mapę topologiczną systemu. Każda strzałka reprezentuje dozwolony przepływ — brak strzałki oznacza zakaz komunikacji. Lateralny ruch między segmentami operatorów w Zone 3 jest bezwzględnie zabroniony. Zone 5 jest dostępna wyłącznie z bastionu — nigdy z terminala operatora ani z workloadu.

Rozdział 26. Kluczowe decyzje architektoniczne

26.1 Thin client jako fundament — dlaczego, co odrzucono, ryzyka rezydualne

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 24.1, 24.2, 25.1, 27.1, 29.2

Decyzja o przyjęciu modelu Thin Client jako fundamentu architektury SYLION jest najważniejszą decyzją architektoniczną platformy. Thin Client oznacza, że terminal operatora (Pixel z GrapheneOS lub zarządzany laptop) pełni wyłącznie rolę urządzenia wejścia/wyjścia — wyświetla piksele, odtwarza audio, przyjmuje input (dotyk, klawiatura, mysz). Żadne dane aplikacyjne, historia komunikacji, klucze sesji ani artefakty pracy nie są przechowywane na terminalu.

Uzasadnienie (dlaczego Thin Client). Model Thin Client eliminuje klasę zagrożeń związanych z utratą lub kompromitacją urządzenia końcowego. W tradycyjnym modelu (fat client) kradzież laptopa operatora oznacza potencjalny dostęp do: historii komunikacji, dokumentów, kluczy kryptograficznych, cache przeglądarki, credentiali. W modelu Thin Client kradzież terminala daje atakującemu: certyfikat IPsec (odwoływalny w ciągu 30 sekund), konfigurację VPN (bezużyteczną bez FIDO2 key), pusty system operacyjny bez danych aplikacyjnych. Skuteczna kompromitacja wymaga jednoczesnego posiadania terminala i klucza FIDO2 i wiedzy o PIN/biometrii — co drastycznie podnosi koszt ataku.

Alternatywy odrzucone. (1) Fat Client z szyfrowaniem dysku: odrzucony, bo szyfrowanie chroni tylko wyłączony urządzenie; uruchomiony terminal z odszyfrowanym dyskiem jest podatny na cold boot, DMA attack, malware. (2) Fat Client z containeryzacją (np. Samsung Knox, Work Profile): odrzucony, bo izolacja kontenerowa na poziomie OS jest wielokrotnie przełamana (CVE w Knox, Android container escape). (3) Virtual Desktop Infrastructure (VDI) z pełnym pulpitem: odrzucony jako domyślny model, bo pełny pulpit daje operatorowi dostęp do filesystem, procesów systemowych, zwiększa attack surface; app-only publishing jest bezpieczniejszą opcją domyślną.

Ryzyka rezydualne. (1) Keylogger na terminalu: jeśli terminal jest skompromitowany (rootkit na GrapheneOS), atakujący może przechwycić input operatora. Mitigacja: hardware attestation (Titan M2 na Pixel weryfikuje integralność OS), regularne re-flash terminala (immutable endpoint). (2) Screen capture: skompromitowany terminal może nagrywać ekran. Mitigacja: operacyjna (polityki fizycznego bezpieczeństwa, DRM-style watermarking na wyświetlanych treściach — eksperymentalne). (3) Latencja sesji: model Thin Client jest wrażliwy na jakość łączności (latencja > 150ms degradowe UX). Mitigacja: adaptacyjne kodowanie (Opus dla audio, VP9/AV1 dla video), lokalne cache UI state (nie danych). (4) Uzależnienie od łączności: brak internetu = brak pracy. Mitigacja: dla scenariuszy terenowych — edge deployment z lokalnym gateway (28.5).

26.2 G1/G2 split gateway — uzasadnienie, alternatywy odrzucone

Status: [N] Normatywny Odbiorca: Architekt | Infra | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 25.2, 25.3, 27.3, 29.3

Split Gateway to architektralna separacja funkcji gateway na dwa odrębne komponenty: G1 (warstwa sieciowa/transportowa) i G2 (warstwa aplikacyjna/polityczna). G1 i G2 muszą działać na odrębnych węzłach obliczeniowych lub w odrębnych TEE — współdzielenie tego samego procesu lub kontenera jest zabronione.

G1 — funkcje i granice. G1 odpowiada za: terminację tunelu IPsec IKEv2 (deszyfrowanie transportu), firewall stateful L3/L4 (filtrowanie pakietów po IP/port/protocol), ochronę anti-DDoS (rate limiting, SYN flood protection), weryfikację certyfikatu klienta IPsec (CRL/OCSP check). G1 jest stateless — nie utrzymuje stanu sesji aplikacyjnej, nie przechowuje tokenów, nie zna tożsamości operatora (zna tylko certyfikat IPsec, który identyfikuje terminal, nie operatora). Kompromitacja G1 daje atakującemu: widzialność ruchu L3/L4 (ale nie treści — warstwa aplikacyjna szyfrowana osobno), możliwość blokowania ruchu (DoS), ale nie możliwość podszywania się pod operatora ani obejścia polityk G2.

G2 — funkcje i granice. G2 odpowiada za: ewaluację polityki dostępu (Policy Engine na bazie OPA), weryfikację tożsamości operatora (OIDC/FIDO2 token), ocenę device posture, routing sesji do właściwego środowiska operatora w Zone 3, trigger CDR dla plików wchodzących/wychodzących, weryfikację attestation (dla TEE w STATE/SOVEREIGN). G2 jest stateful — utrzymuje stan sesji, token lifecycle, cache polityk. Kompromitacja G2 jest scenariuszem krytycznym — wymaga natychmiastowej rewokacji wszystkich sesji, revalidacji tożsamości i potencjalnego rebuildu.

Uzasadnienie separacji. Separacja G1/G2 zapewnia: (1) defense in depth — atakujący musi przełamać dwa niezależne komponenty, (2) ograniczenie blast radius — kompromitacja G1 nie daje dostępu do polityk ani danych sesji, (3) niezależne skalowanie — G1 skaluje się horyzontalnie (load balancer, anycast), G2 skaluje się per tenant cluster, (4) niezależną certyfikację — G1 (transport/FIPS) i G2 (application/CC) mogą być certyfikowane niezależnie.

Alternatywy odrzucone. (1) Monolityczny gateway: odrzucony — single point of compromise, brak separacji warstw, trudność certyfikacji. (2) Reverse proxy (nginx/HAProxy) jako gateway: odrzucony — brak natywnej integracji z IPsec, brak policy engine, niewystarczająca izolacja. (3) Service mesh jako gateway (Istio/Linkerd): odrzucony — zbyt duża złożoność, brak kontroli nad transport layer, nieprzejrzysty model zaufania.

26.3 Per-operator isolation — model izolacji, granice, wyjątki

Status: [N] Normatywny Odbiorca: Architekt | Infra | Dev | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 25.2, 25.3, 27.5, 29.4, 30.2

Per-operator isolation oznacza, że każdy operator działa w kryptograficznie, sieciowo i obliczeniowo izolowanym środowisku. Izolacja nie opiera się na jednym mechanizmie — jest wielowarstwowa.

Warstwa 1: Izolacja sieciowa. Każdy operator ma dedykowany network namespace (lub VXLAN segment) w Zone 3. Ruch między segmentami operatorów jest blokowany na poziomie eBPF/nftables — nie istnieje ścieżka sieciowa z segmentu Operatora A do segmentu Operatora B. Nawet jeśli dwa segmenty działają na tym samym węźle fizycznym, kernel network namespace zapewnia izolację na poziomie jądra. Dodatkowa warstwa: IPsec transport między G2 a workloadem per operator (opcjonalnie dla STATE/SOVEREIGN — transport within zone encrypted).

Warstwa 2: Izolacja obliczeniowa. Każdy workload operatora działa w dedykowanej microVM Firecracker. Firecracker zapewnia izolację na poziomie hypervisora (KVM) — exploity na poziomie user-space jednego workloadu nie mają ścieżki do innego workloadu. MicroVM ma minimalny kernel (stripped Linux), minimalny rootfs (Alpine/NixOS), read-only filesystem (z wyjątkiem ephemeral storage). Boot time: <150ms, memory overhead: <5MB per microVM.

Warstwa 3: Izolacja kryptograficzna. Każdy operator posiada odrębny zestaw kluczy: klucz szyfrowania storage (derived from HSM, per operator), klucze sesji Matrix (Olm/Megolm, per operator, per room), certyfikat mTLS workloadu (per operator, per workload type). Klucze operatora A nie są dostępne dla operatora B — nawet dla administratora platformy (klucze w HSM, no key export).

Warstwa 4: Izolacja na poziomie pamięci (STATE/SOVEREIGN). Confidential Computing (AMD SEV-SNP / Intel TDX) zapewnia, że pamięć operacyjna microVM operatora jest zaszyfrowana kluczem sprzętowym — operator infrastruktury (hypervisor admin) nie może odczytać danych w pamięci.

Wyjątki od pełnej izolacji. (1) Shared services (Zone 4): CDR engine, log collector, egress proxy — są współdzielone między operatorami. Izolacja na poziomie usługi: każdy request jest uwierzytelniany per operator, dane nie są mieszane. CDR przetwarza pliki w efemerycznych microVM — per file, nie per operator (izolacja na poziomie procesu). (2) Komunikacja Matrix między operatorami tego samego tenanta: dozwolona przez homeserver (shared room), ale szyfrowana E2E (operatorzy wymieniają klucze Megolm, homeserver widzi tylko ciphertext). (3) Komunikacja głosowa między operatorami tego samego tenanta: dozwolona przez media relay w Zone 3, z E2E encryption (SRTP/DTLS).

26.4 App-only publishing jako baseline — dłączego pełny pulpit jest [R] nie [N]

Status: [N] Normatywny (app-only jako default) | [R] Rekomendowany (full desktop jako opcja) Odbiorca: Architekt | Dev | Klient | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 17.2, 24.2, 24.6, 26.1, 27.5

App-only publishing oznacza, że operator widzi na swoim terminalu poszczególne aplikacje (workloady) jako oddzielne okna lub panele — nie widzi pełnego pulpitu systemu operacyjnego z menedżerem plików, terminalem, ustawieniami systemowymi. Jest to domyślny i normatywny model interakcji.

Uzasadnienie app-only jako baseline. (1) Zredukowany attack surface: operator nie ma dostępu do shell, filesystem, system processes — co eliminuje klasę ataków opartych na local privilege escalation, file system traversal, process injection. (2) Uproszczony audyt: w modelu app-only system wie dokładnie, jakie aplikacje operator używa — log jest precyzyjny (operator otworzył env-matrix o 14:32, zamknął o 15:47). W modelu full desktop log musiałby obejmować każdą operację filesystem i procesów — generując szum. (3) Kontrolowany clipboard i DLP: w modelu app-only clipboard między workloadami jest kontrolowany przez session broker (per workload, per tier). W modelu full desktop operator może użyć system clipboard, co utrudnia kontrolę. (4) Prostsza polityka egress: w modelu app-only każdy workload ma zdefiniowany profil egress (env-browser → egress proxy, env-signal → Signal egress, env-matrix → Matrix homeserver). W modelu full desktop operator może próbować otworzyć dowolną aplikację sieciową.

Pełny pulpit jako opcja [R]. Pełny pulpit jest dostępny jako opcja rekomendowana dla zaawansowanych użytkowników i scenariuszy wymagających pełnego środowiska (np. programiści, administratorzy systemów klienta). Aktywacja pełnego pulpitu wymaga jawnej decyzji TENANT_ADMIN i jest logowana jako zmiana konfiguracji. W trybie full desktop: filesystem jest nadal read-only (z wyjątkiem dedykowanego /home), shell jest dostępny (ale logowany), DLP i CDR nadal działają na egress. Bezpieczeństwo: pełny pulpit podlega wzmocnionemu monitoringowi (session recording rekomendowane).

Ryzyka pełnego pulpitu. Operator może: instalować nieautoryzowane narzędzia (mitigacja: read-only rootfs, brak sudo), próbować obchodzić DLP (mitigacja: egress proxy z deep inspection), eksponować system processes (mitigacja: container hardening, seccomp, AppArmor). Pełny pulpit nigdy nie stanie się normatywnym — architektura SYLION jest zaprojektowana wokół modelu app-only.

26.5 Matrix jako rdzeń — uzasadnienie, ryzyka, alternatywy odrzucone

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Dev | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 24.2, 24.6, 26.6, 27.5

Matrix (protokół i ekosystem) został wybrany jako rdzeń komunikacyjny SYLION — podstawowy kanał tekstowy, głosowy i wideo. Decyzja ta jest normatywna i fundamentalna dla architektury.

Uzasadnienie. (1) Kontrolowana federacja: Matrix pozwala na uruchomienie własnego homeservera z pełną kontrolą nad danymi, politykami i federacją. Federacja może być ograniczona do approved list — co umożliwia komunikację międzyorganizacyjną (operator SYLION tenanta A ↔ operator tenanta B) bez ujawniania danych podmiotom trzecim. (2) Otwartość protokołu: Matrix jest protokołem otwartym (specyfikacja publiczna, multiple implementations), co eliminuje vendor lock-in i umożliwia audyt kodu. Implementacja referencyjna (Synapse/Dendrite) jest open-source. (3) Zaawansowane szyfrowanie E2E: Olm (1:1) i Megolm (grupowe) zapewniają szyfrowanie end-to-end z forward secrecy. Klucze zarządzane per device — kompromitacja jednego urządzenia nie daje dostępu do historii. (4) Rozbudowany model uprawnień: pokoje (rooms) z granularnym RBAC (power levels), spaces (hierarchia pokoi), polityki moderacji. (5) API i integracja: Matrix ma bogatą specyfikację API (Client-Server API, Server-Server API, Application Service API) umożliwiającą integrację z botami, bridgami i zewnętrznymi systemami. (6) Głos i wideo: natywna obsługa VoIP (WebRTC-based) z możliwością integracji z Jitsi/LiveKit dla grupowych rozmów.

Ryzyka. (1) Dojrzałość implementacji: Synapse (referencyjna implementacja Python) ma historię problemów z wydajnością i stabilnością przy dużej skali. Mitigacja: SYLION używa Dendrite (Go implementation, wyższa wydajność) lub Conduit (Rust implementation) — z ciągłym monitoringiem stabilności. (2) Złożoność protokołu: specyfikacja Matrix jest obszerna i ewoluuje — potencjalne ryzyko incompatible changes. Mitigacja: pinning wersji specyfikacji, testy kompatybilności. (3) Metadata leakage: nawet z E2E encryption, homeserver widzi metadane (kto rozmawia z kim, kiedy, jak często). Mitigacja: homeserver jest pod kontrolą SYLION/klienta (nie podmiot trzeci), metadane chronione jak dane operacyjne. (4) Key management complexity: cross-signing, device verification, key backup — złożone i podatne na błędy użytkownika. Mitigacja: automatyzacja key management w session lifecycle, FIDO2-backed key verification.

Alternatywy odrzucone. (1) Signal jako rdzeń: odrzucony — wymaga numeru telefonu, brak kontrolowalnej federacji, infrastruktura pod kontrolą Signal Foundation (patrz 26.6). (2) XMPP: odrzucony — fragmentacja ekosystemu (setki XEPów, nierównomierna implementacja), brak natywnego E2E encryption w standardzie bazowym, mniejsza aktywna społeczność. (3) Proprietary protocol (custom): odrzucony — nie audytowalny przez społeczność, brak zewnętrznego peer review, vendor lock-in. (4) Mattermost/Rocket.Chat: odrzucone — brak federacji, brak E2E encryption w modelu bazowym, architektura monolityczna.

26.6 Signal jako workload kompatybilności — dlaczego zdegradowany, kiedy dopuszczalny

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 24.3, 24.6, 26.5, 27.5, 29.2

Signal jest traktowany w architekturze SYLION jako workload kompatybilności — nie jako podstawowy kanał komunikacyjny. Decyzja o degradacji Signal z roli rdzenia do roli „compatibility wrapper” jest świadoma i udokumentowana.

Dlaczego Signal jest zdegradowany. (1) Rejestracja numerem telefonu: Signal wymaga numeru telefonu do rejestracji konta. W kontekście operatorów wymagających ochrony tożsamości (służby specjalne, dyplomacja, infrastruktura krytyczna) ujawnienie numeru telefonu jest nieakceptowalnym ryzykiem. Numer telefonu jest de facto globalnym identyfikatorem umożliwiającym korelację tożsamości. (2) Brak kontrolowanej federacji: Signal jest zamkniętym ekosystemem — nie można uruchomić własnego serwera Signal i sfederować go z oficjalną siecią. Komunikacja przechodzi przez serwery Signal Foundation (US jurisdiction). Dla klientów sovereign to eliminujący czynnik. (3) Brak zaawansowanych polityk: Signal nie obsługuje RBAC, grup z hierarchią uprawnień, spaces, integracji API na poziomie Matrix. Zarządzanie komunikacją w organizacji o złożonej strukturze jest praktycznie niemożliwe. (4) Zależność od infrastruktury trzeciej strony: awaria serwerów Signal Foundation oznacza brak komunikacji. SYLION nie kontroluje dostępności ani polityki bezpieczeństwa Signal. (5) Ograniczone możliwości audytu: Signal celowo minimalizuje metadane (co jest zaletą w kontekście prywatności indywidualnej), ale jest problemem w kontekście korporacyjnym, gdzie audyt komunikacji jest wymaganiem regulacyjnym.

Kiedy Signal jest dopuszczalny. Signal jest dopuszczalny wyłącznie jako workload kompatybilności (env-signal) do komunikacji z podmiotami zewnętrznymi, które nie używają Matrix i preferują Signal. Typowe scenariusze: komunikacja z kontaktem zewnętrznym (dziennikarz, informator, partner biznesowy), który używa Signal; komunikacja z organizacją, która wdrożyła Signal jako standard wewnętrzny. W tych scenariuszach: env-signal działa w izolowanej microVM z dedykowanym egress, nie ma połączenia z env-matrix ani innymi workloadami, komunikacja przez Signal nie jest archiwizowana w infrastrukturze SYLION (E2E encryption przez Signal), ale fakt sesji Signal (metadane: czas, czas trwania) jest logowany.

Ryzyka rezydualne. Operator może próbować używać Signal do komunikacji wewnętrznej (zamiast Matrix), omijając audyt. Mitigacja: monitoring częstotliwości użycia env-signal, alertowanie na anomalne wzorce, polityka organizacyjna (Signal = only external, Matrix = all internal).

26.7 IPsec IKEv2 jako jednolity stos — decyzja vs WireGuard, FIPS/CNSA 2.0 wymóg

Status: [N] Normatywny Odbiorca: Architekt | Infra | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 24.4, 24.6, 25.2, 27.2, 29.6

IPsec IKEv2 (implementacja: strongSwan) jest jedynym dozwolonym protokołem transportu VPN w architekturze SYLION. Decyzja ta jest normatywna i wynika z wymagań certyfikacyjnych, kryptograficznych i operacyjnych.

Uzasadnienie IPsec IKEv2. (1) Walidacja FIPS 140-3: strongSwan posiada ścieżkę do walidacji FIPS 140-3 (moduł kryptograficzny). WireGuard nie posiada walidacji FIPS 140-3 i nie jest planowana (ChaCha20/Poly1305 nie jest w FIPS approved list, a Curve25519 nie jest w CNSA suite). (2) CNSA 2.0 compliance: NSA CNSA 2.0 wymaga AES-256 + SHA-384 + ECDH P-384 (lub PQC equivalent) dla transportu classified. IPsec IKEv2 ze strongSwan wspiera pełny CNSA 2.0 suite. WireGuard nie — jest hard-coded na ChaCha20/Poly1305 + Curve25519. (3) IKE negotiation: IKEv2 zapewnia dynamiczną negocjację parametrów kryptograficznych (cipher suite, DH group, lifetime) — co umożliwia hybrydowy PQC key exchange (classical ECDH + ML-KEM). WireGuard używa stałych, hardcoded kluczy — brak dynamicznego rekeying w modelu standardowym. (4) Client certificate authentication: IKEv2 natywnie wspiera uwierzytelnianie certyfikatem X.509 — terminal prezentuje certyfikat wystawiony przez PKI SYLION. WireGuard używa pre-shared keys lub static public keys — brak integracji z PKI. (5) Dojrzałość i audytowalność: IPsec/IKEv2 jest standardem IETF z 20+ letnią historią, przeszedł liczne audyty, jest certyfikowany w wielu implementacjach. WireGuard jest młodszy, prostszy (co jest zaletą w wielu kontekstach), ale brak historii certyfikacji.

WireGuard — dlaczego odrzucony jako transport główny. WireGuard jest technicznie elegancki (mały codebase, wysoka wydajność, prosty protokół) i jest doskonałym rozwiązaniem dla wielu use case'ów. Jednak dla SYLION kluczowe są wymagania, których WireGuard nie spełnia: FIPS 140-3 (brak), CNSA 2.0 (brak), hybrid PQC key exchange (brak native support), PKI integration (brak native support), dynamic rekeying (limited). WireGuard może pojawić się wyłącznie w eksperymentalnym kontekście mesh overlay (FN-X04) — nigdy jako transport główny.

Ryzyka rezydualne. (1) Złożoność konfiguracji IPsec: IPsec jest bardziej złożony niż WireGuard — ryzyko misconfiguracji. Mitigacja: konfiguracja generowana przez IaC (Ansible), walidowana automatycznie, testowana w CI/CD. (2) Overhead wydajnościowy: IPsec (AES-256-GCM) ma wyższy overhead niż WireGuard (ChaCha20). Mitigacja: AES-NI (hardware acceleration) na serwerach i terminalach — overhead negligible. (3) Fragmentacja ekosystemu: strongSwan, Libreswan, FreeS/WAN — wiele implementacji. SYLION standaryzuje wyłącznie na strongSwan.

26.8 HSM/PKI/PQC w rdzeniu — architektura zaufania, certifiable boundary

Status: [N] Normatywny Odbiorca: Architekt | Compliance | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 24.4, 26.7, 27.8, 30.6

Hardware Security Module (HSM) stanowi korzeń zaufania (root of trust) kryptograficznego w architekturze SYLION. Cała hierarchia PKI, podpisywanie polityk i generowanie kluczy sesji opiera się na materiale kluczowym, który nigdy nie opuszcza granicy fizycznej HSM.

Hierarchia PKI. Root CA → Intermediate CA (per tenant) → End-entity certificates (per operator, per workload, per service). Root CA key: generowany wewnątrz HSM (FIPS 140-3 Level 3), nigdy eksportowany, operacje podpisywania wyłącznie w HSM boundary. Intermediate CA key: generowany w HSM, opcjonalnie exportable (dla sovereign deployments z customer-managed HSM). End-entity certificates: generowane dynamicznie (Vault PKI, backed by HSM), krótki lifetime (24h dla workload certificates, 30 dni dla operator certificates).

HSM tiers. STANDARD: software HSM (SoftHSM2) lub cloud KMS (AWS KMS, Azure Key Vault) — akceptowalne dla tier STANDARD. PRO: cloud dedicated HSM (AWS CloudHSM, Azure Dedicated HSM) — FIPS 140-3 Level 3, dedykowany tenant. STATE/SOVEREIGN: on-premise HSM (Thales Luna, Utimaco, nCipher nShield) — pod wyłączną kontrolą klienta, FIPS 140-3 Level 3, fizycznie w lokalizacji klienta. Ceremonia generowania root CA key: procedura z dwuosobową autoryzacją (dual custody), świadkowie, nagranie, dokumentacja.

Post-Quantum Cryptography (PQC). HSM musi być PQC-capable: obsługa algorytmów ML-KEM (Kyber) i ML-DSA (Dilithium) zgodnie z NIST FIPS 203/204. Status: (1) PQC-ready (opcjonalnie) od Q3 2026 — hybrydowy key exchange (ECDH + ML-KEM), hybrydowe certyfikaty (ECDSA + ML-DSA). (2) PQC-mandatory dla nowych wdrożeń STATE/SOVEREIGN od Q1 2027. (3) PQC-only (target 2030, zależny od standardów CNSA 2.0). Hybrid mode: obie kryptosystemy (klasyczny i PQC) muszą być złamane jednocześnie, aby kompromitacja była skuteczna — zapewnia bezpieczeństwo w okresie przejściowym.

Certifiable boundary. HSM i PKI stanowią certifiable boundary: granicę modułu kryptograficznego podlegającego formalnej certyfikacji (FIPS 140-3). Wewnątrz boundary: generowanie kluczy, podpisywanie, szyfrowanie, zarządzanie lifecycle kluczy. Zewnątrz boundary: aplikacje wywołujące operacje kryptograficzne przez PKCS#11 API. Boundary musi być udokumentowana, testowana i audytowana niezależnie od reszty systemu.

26.9 Immutable / rebuild-first — model operacyjny, co to znaczy w praktyce

Status: [N] Normatywny Odbiorca: Architekt | Infra | Dev | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.4, 24.2, 27.7, 29.7, 29.8

Immutable infrastructure w kontekście SYLION oznacza, że żaden komponent produkcyjny nie jest modyfikowany in-place. Aktualizacja = zbuduj nowy obraz → zweryfikuj → wdróż obok starego → przełącz ruch → zniszcz stary. Patching in-place (SSH na serwer, apt upgrade) jest zabroniony.

Co oznacza immutable w praktyce. (1) Obrazy microVM (Firecracker): budowane w CI/CD pipeline, podpisane (Cosign), wdrażane przez orchestration. Aktualizacja workloadu: nowy obraz → nowa microVM → migracja sesji → zniszczenie starej microVM. Czas: <30 sekund (downtime per operator <5 sekund). (2) Obrazy kontenerów (Zone 4/5 services): budowane w CI/CD, skanowane (Trivy), podpisane, wdrażane przez GitOps (Flux/ArgoCD). Drift detection: continuous scanning porównuje running state z desired state (Git) — odchylenie = alert + automatic rollback. (3) Konfiguracja infrastruktury (Terraform): state przechowywany w encrypted backend, zmiany wyłącznie przez PR z peer review → plan → apply. Manual terraform apply bez PR: zabronione. (4) System operacyjny hostów (baremetal/VM): immutable OS (Flatcar/Talos Linux) — read-only rootfs, konfiguracja przez cloud-init/ignition, aktualizacja przez reboot do nowego obrazu (A/B partition scheme). Brak SSH na hostach produkcyjnych (poza break-glass scenario z audit trail).

Rebuild-first principle. W przypadku podejrzenia kompromitacji: nie diagnozuj, nie patchuj — zniszcz i odbuduj z czystego stanu (laC). Rebuild flow: (1) izoluj podejrzaną komponent (network quarantine), (2) zachowaj forensic snapshot (dla analizy post-incident), (3) zniszcz komponent, (4) odbuduj z laC (Terraform destroy → apply), (5) zweryfikuj (automated tests), (6) przywróć ruch. Czas rebuildu: <30 minut per operator environment, <4 godzin per full platform.

Wyjątki od immutability. (1) HSM: HSM jest fizycznym urządzeniem — firmware update wymaga procedury (podpisany firmware, dual custody). (2) Terraform state: mutable by design (sequential apply) — chroniony encryption + access control. (3) Log store: append-only (not immutable in the rebuild sense, but tamper-evident). (4) Secrets (Vault): mutable (rotation) — chronione audit trail + access policy.

26.10 Controlled file transfer — CDR jako obowiązkowy kanał, co CDR robi i czego nie

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 17.3, 24.2, 27.6, 30.4, 31.3

Content Disarm and Reconstruction (CDR) jest obowiązkowym mechanizmem dla każdego pliku wchodzącego do Zone 3. Żaden plik — niezależnie od źródła, formatu, rozmiaru — nie może ominąć pipeline CDR.

Co CDR robi. (1) Parsowanie: plik jest parsowany w efemerycznej microVM (Firecracker, dedykowany obraz CDR). Parser identyfikuje format (PDF, DOCX, XLSX, PPTX, JPG, PNG, ZIP, etc.) i weryfikuje zgodność z deklarowanym typem MIME. (2) Rekonstrukcja: plik jest rozbierany na elementy składowe (tekst, obrazy, tabele, metadata) i rekonstruowany od zera w czystym formacie. Aktywne treści (makra VBA, JavaScript w PDF, Flash, ActiveX, embedded objects, OLE links) są usuwane. Metadata (author, creation date, GPS coordinates, revision history) — usuwane domyślnie, opcjonalnie zachowywane per policy. (3) Sanityzacja obrazów: obrazy embedded w dokumentach są rekonstruowane (dekodowanie → re-encoding) — eliminuje steganografię i exploity w parserach obrazów. (4) Walidacja struktury: zrekonstruowany plik jest walidowany pod kątem poprawności strukturalnej (well-formed document). Niepoprawne pliki → kwarantanna.

Czego CDR nie robi. (1) CDR nie wykrywa malware: CDR nie jest antywirusem. Nie skanuje pliku w poszukiwaniu known signatures. CDR eliminuje aktywne treści — nawet jeśli nie wie, że są złośliwe. Podejście: assume everything is hostile, remove everything active. (2) CDR nie chroni przed social engineering: zrekonstruowany dokument może zawierać tekst phishingowy — CDR nie analizuje treści semantycznie. (3) CDR nie obsługuje wszystkich formatów: formaty nieobsługiwane (np. custom binary, encrypted ZIP) → kwarantanna + alert do operatora. Lista obsługiwanych formatów: PDF, DOCX/XLSX/PPTX, ODT/ODS/ODP, JPG/PNG/GIF/BMP/TIFF, SVG, HTML (sanitized), CSV, TXT, ZIP (rekursywne przetwarzanie zawartości). (4) CDR nie jest odwracalny: oryginalny plik (pre-CDR) jest przechowywany w quarantine storage (encrypted, retention per policy) — ale operator otrzymuje wyłącznie zrekonstruowaną wersję.

Pipeline CDR krok po kroku. (1) Upload: plik trafia do staging area (Zone 4, encrypted temporary storage). (2) Klasyfikacja: format identification (libmagic + deep inspection). (3) Routing: plik kierowany do odpowiedniego parsera w efemerycznej microVM CDR. (4) Processing: parse → disarm → reconstruct (w microVM, timeout 60s per file, max 100MB per file). (5) Validation: output validated, checksum computed. (6) Delivery: zrekonstruowany plik dostarczony do workloadu żądającego (Zone 3). (7) Audit: pełny log (file hash pre/post, format, processing time, decision) zapisany w Zone 4. (8) Cleanup: staging area wyczyszczona, microVM CDR zniszczona.

26.11 Control plane vs media plane — separacja, uzasadnienie

Status: [N] Normatywny Odbiorca: Architekt | Infra | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 25.2, 27.3, 27.4, 27.5, 29.1

Architektura SYLION separuje control plane (płaszczyzna sterowania) od media plane (płaszczyzna danych/mediów). Separacja ta jest realizowana sieciowo, obliczeniowo i logicznie.

Control plane — definicja i zakres. Control plane obejmuje: Policy Engine (decyzje dostępu), Session Broker (zarządzanie sesją), IAM/IdP (tożsamość), laC/automation (provisioning), monitoring (health, alerting), secrets management (Vault). Control plane nie przetwarza treści sesji operatora — widzi metadane (kto, kiedy, do czego, decyzja allow/deny), ale nie treść (tekst wiadomości, zawartość dokumentów, audio rozmowy). Control plane działa w Zone 5 (management) i Zone 2 (gateway, warstwa sterowania G2).

Media plane — definicja i zakres. Media plane obejmuje: pixel streaming (wyświetlanie treści sesji), audio transport (Opus), Matrix messaging (Olm/Megolm ciphertext), file transfer (CDR pipeline), browser egress (HTTPS traffic), voice media (SRTP/DTLS). Media plane przetwarza treść sesji operatora — ale w formie zaszyfrowanej (E2E encryption dla komunikacji Matrix, szyfrowanie sesji dla pixel streaming). Media plane działa w Zone 3 (workloady) i Zone 4 (shared services: CDR, egress proxy).

Uzasadnienie separacji. (1) Bezpieczeństwo: kompromitacja control plane nie daje dostępu do treści sesji (treść szyfrowana kluczami E2E, do których control plane nie ma dostępu). Kompromitacja media plane nie daje kontroli nad politykami, tożsamością, provisioning. (2) Skalowalność: control plane i media plane skalują się niezależnie. Control plane skaluje się z liczbą decyzji (policy evaluations per second). Media plane skaluje się z liczbą sesji i throughputem (bandwidth per session). (3) Latencja: media plane wymaga niskiej latencji (pixel streaming: <50ms RTT target, audio: <150ms RTT). Control plane toleruje wyższą latencję (policy evaluation: <100ms, provisioning: sekundy). Separacja pozwala na optymalizację osobno. (4) Audyt: control plane generuje logi decyzji (kto, co, kiedy, decyzja). Media plane generuje logi przepływu (ile danych, czas trwania, jakość). Separacja logów ułatwia compliance (audytor widzi decyzje, nie treści).

Punkty styku. Control plane i media plane spotykają się w G2: G2 podejmuje decyzję (control plane) i kieruje ruch sesji do workloadu (media plane routing). Session Broker w G2 utrzymuje stan sesji (control plane: token, policy cache) i monitoruje heartbeat sesji (media plane: liveness probe). Punkty styku są zdefiniowane i ograniczone — nie istnieje swobodna komunikacja między płaszczyznami.

26.12 Certifiable core vs moduły autonomiczne — co wchodzi do certyfikacji, co pozostaje poza

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 24.2, 24.7, 25.1, 26.9, 29.1

Architektura SYLION rozdziela system na certifiable core (rdzeń podlegający formalnej certyfikacji) i autonomous modules (moduły poza zakresem certyfikacji). Podział jest intencjonalny — obejmuje certyfikacją wyłącznie komponenty krytyczne dla bezpieczeństwa, co umożliwia praktyczną certyfikowalność (CC EAL4+, FIPS 140-3) bez paraliżowania rozwoju.

Certifiable core — skład. (1) Kryptografia: HSM integration (PKCS#11), PKI (Vault CA), IPsec/strongSwan transport module, E2E encryption libraries (Olm/Megolm). (2) Kontrola dostępu: G2 Policy Engine (OPA), Session Broker, IAM core (Keycloak authentication flows). (3) Izolacja: Firecracker microVM orchestration, network micro-segmentation (eBPF/nftables rules), Zone boundary enforcement. (4) Transfer kontrolowany: CDR engine, DLP engine. (5) Audit: log pipeline (collector → immutable store), event format specification.

Autonomous modules — skład. (1) Admin Portal (frontend + backend). (2) Monitoring stack (Prometheus, Grafana, Loki). (3) CI/CD pipeline (GitLab CI, Trivy, Cosign). (4) Backup system (Restic/Borg). (5) Knowledge Base. (6) Ticketing system. (7) AI-assisted analysis (FN-X01). (8) Workload-specific applications (LibreOffice, Chromium, CRM — te mają own security posture, ale nie wchodzą do certyfikacji SYLION).

Zasady granicy. (1) Autonomiczny moduł nie może modyfikować stanu certifiable core inaczej niż przez zdefiniowane API. (2) Awaria autonomicznego modułu nie może wpłynąć na bezpieczeństwo core (fail-safe). (3) Core nie zależy od autonomicznych modułów — jeśli Admin Portal jest niedostępny, core nadal działa (operatorzy mogą nawiązywać sesje, polityki są egzekwowane, logi zbierane). (4) Aktualizacje autonomicznych modułów nie wymagają re-certyfikacji core. (5) Core components mają zamrożone wersje (version pinning per release) — autonomiczne moduły mogą być aktualizowane niezależnie.

Implikacje dla rozwoju. Certifiable core ewoluuje powoli (quarterly releases, full security review per release). Autonomiczne moduły ewoluują szybko (continuous delivery). Nowe funkcje: najpierw jako autonomiczny moduł (pilot, feedback), potem — jeśli krytyczne dla bezpieczeństwa — migracja do core (z full review i re-certyfikacją). Nigdy odwrotnie: raz certyfikowany komponent nie wraca do statusu autonomicznego.

26.13 Elementy odrzucone względem FORTRESS — WireGuard, Signal jako rdzeń, Tails OS na VPS, zbyt agresywne twierdzenia o anonimowości

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 24.6, 26.5, 26.6, 26.7, 29.2

SYLION jest ewolucją koncepcji FORTRESS — wcześniejszego projektu architektury bezpiecznej komunikacji. Podczas projektowania SYLION 3.0 dokonano przeglądu decyzji FORTRESS i świadomie odrzucono kilka elementów, które okazały się architektonicznie wadliwe, niecertyfikowalne lub oparte na błędnych założeniach.

WireGuard jako transport VPN (odrzucony). FORTRESS używał WireGuard jako domyślnego transportu. SYLION odrzucił WireGuard na rzecz IPsec IKEv2 z następujących powodów: brak FIPS 140-3 validation (eliminujący dla STATE/SOVEREIGN), brak CNSA 2.0 compliance, brak dynamicznego rekeying (static keys), brak integracji z PKI (X.509 certificates), brak native support dla hybrid PQC key exchange. Szczegółowe uzasadnienie: patrz 26.7.

Signal jako rdzeń komunikacyjny (odrzucony). FORTRESS traktował Signal jako podstawowy kanał. SYLION zdegradował Signal do roli compatibility workload: wymóg numeru telefonu (privacy concern), brak kontrolowanej federacji, infrastruktura pod kontrolą Signal Foundation (US jurisdiction, brak sovereign option), brak zaawansowanych polityk (RBAC, spaces, API), ograniczone możliwości audytu. Szczegółowe uzasadnienie: patrz 26.5, 26.6.

Tails OS na VPS (odrzucony). FORTRESS rozważał uruchomienie Tails OS jako systemu operacyjnego workloadu w VPS. SYLION odrzucił tę koncepcję: Tails jest zaprojektowany jako system stacjonarny z amnezycznym storage (RAM-only) — korzyść ta jest bezprzedmiotowa na VPS, gdzie hypervisor ma dostęp do storage i pamięci (chyba że TEE). Tails nie jest zoptymalizowany pod Firecracker/microVM (wymaga custom bootloadera, dużo RAM, długi boot). Tails kieruje cały ruch przez Tor — w kontekście SYLION (IPsec transport) dodanie warstwy Tor jest nadmiarowe i degradowa wydajność. Workloady SYLION używają minimalnych obrazów Alpine/NixOS, zoptymalizowanych pod Firecracker: <50MB rootfs, <150ms boot, read-only filesystem.

Zbyt agresywne twierdzenia o anonimowości (odrzucone). FORTRESS w materiałach koncepcyjnych zawierał twierdzenia o „anonimowym dostępie” i „nieidentyfikowalnych operatorach”. SYLION odrzuca te twierdzenia: system jest zaprojektowany dla identyfikowalności (każdy operator ma tożsamość, każda sesja jest audytowana). Anonimowość i audytowalność są wzajemnie sprzeczne — nie można jednocześnie twierdzić, że system jest w pełni anonimowy i w pełni audytowalny. SYLION wybiera audytowalność. Pseudonimowość (operator znany pod pseudonimem) jest dopuszczalna — ale system zawsze zna tożsamość rzeczywistą na poziomie administracyjnym. Twierdzenia o anonimowości są wykluczone z materiałów marketingowych, dokumentacji technicznej i umów.

Inne elementy odrzucone z FORTRESS. (1) Onion routing (Tor integration): odrzucony — dodaje latencję (3+ hops), nie jest potrzebny przy IPsec transport, komplikuje audyt, ryzyko exit node compromise. (2) Self-destructing messages: odrzucone jako funkcja baseline — sprzeczne z audytowalnością; dostępne opcjonalnie per policy (ale log o fakcie wysłania self-destructing message jest zachowywany). (3) Steganographic communication: odrzucone — niewystarczająco dojrzałe, trudne do audytu, false sense of security.

Rozdział 27. Przegląd modułów i zależności

27.1 Endpoint layer — komponenty, zależności, granice odpowiedzialności

Status: [N] Normatywny Odbiorca: Architekt | Infra | Dev Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 24.2, 25.1, 26.1, 28.7, 31.1

Endpoint layer (Zone 0) obejmuje wszystkie urządzenia końcowe operatorów i routery sieciowe. Warstwa ta jest jedynym elementem systemu znajdującym się fizycznie poza kontrolą infrastrukturalną SYLION — dlatego jest traktowana jako semi-trusted.

Komponent EP-01: Terminal mobilny (Pixel + GrapheneOS). Sprzęt: Google Pixel 7a/8/8 Pro (lub nowszy). OS: GrapheneOS (hardened AOSP fork). Software na terminalu: strongSwan VPN client (IPsec IKEv2), remote session client (Apache Guacamole client lub Spice/RDP thin client), Titan M2 security chip (FIDO2 credential storage). Dane trwałe na terminalu: certyfikat klienta IPsec (X.509, auto-renewed), konfiguracja VPN (server address, CA cert), FIDO2 credential (hardware-bound w Titan M2). Dane nietrwałe: pixel/audio stream buffer (RAM only, cleared on session end). Konfiguracja: profile zarządzany centralnie (MDM-like, GrapheneOS profile owner), automatyczny update OS, automatyczny renewal certyfikatu.

Komponent EP-02: Terminal laptopowy (Managed Laptop). Sprzęt: laptop z TPM 2.0. OS: hardened Linux (Fedora Silverblue/NixOS) lub managed Windows (z Intune). Software: strongSwan VPN client, remote session client, FIDO2 support. Konfiguracja: zarządzana przez Ansible/laC, FDE (Full Disk Encryption) wymagane, Secure Boot wymagane. Laptop jest traktowany identycznie jak terminal mobilny — thin client, brak danych aplikacyjnych.

Komponent EP-03: Router sieciowy (opcjonalny). Dedykowany router (GL.iNet Beryl lub Flint) z pre-konfigurowanym tunelem IPsec do G1. Cel: operator podłącza terminal do routera (WiFi lub Ethernet), router zestawia tunel — terminal nie musi zestawiać VPN samodzielnie. Use case: hotel, biuro klienta, środowisko o ograniczonej kontroli sieci. Router jest stateless — konfiguracja wgrana fabrycznie (laC), brak danych operacyjnych, reset-to-factory w 30 sekund.

Zależności warstwy endpoint. (1) PKI (Zone 5): endpoint potrzebuje certyfikatu IPsec — zależność od Vault PKI/HSM. (2) G1 (Zone 2): endpoint zestawia tunel IPsec do G1 — zależność od dostępności G1. (3) NTP (Zone 4): endpoint synchronizuje czas — zależność od NTP (pośrednio, przez OS). (4) MDM/Profile management (Zone 5): konfiguracja terminala — zależność od management plane.

Granice odpowiedzialności. Endpoint layer odpowiada za: zestawienie tunelu, prezentację sesji, ochronę FIDO2 credential, integralność OS (przez GrapheneOS/hardened Linux). Endpoint layer nie odpowiada za: bezpieczeństwo danych (brak danych), autoryzację (G2), polityki (Policy Engine), treść sesji (workloady Zone 3).

27.2 Access layer — router, tunel, kill switch

Status: [N] Normatywny Odbiorca: Architekt | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 25.2, 26.7, 27.1, 27.3

Access layer (Zone 1) obejmuje sieć od terminala do gateway, ze wszystkimi mechanizmami zapewniającymi poufność, integralność i dostępność transportu.

Komponent AC-01: Tunel IPsec IKEv2. Implementacja: strongSwan (klient na terminalu, responder na G1). Parametry kryptograficzne (CNSA 2.0 target): IKE SA: AES-256-GCM + SHA-384 + ECDH P-384 (klasyczny) + ML-KEM-768 (hybrydowy PQC, opcjonalnie). Child SA: AES-256-GCM + SHA-384. Certificate authentication: X.509 certyfikat klienta (wystawiony przez PKI SYLION, 30-day lifetime, auto-renewed). IKE SA lifetime: 24h. Child SA rekey: 1h. Dead Peer Detection (DPD): 30s interval, 3 retries.

Komponent AC-02: Kill switch. Mechanizm: nftables/iptables rule set na terminalu blokujący cały ruch sieciowy, który nie przechodzi przez tunel IPsec. Cel: zapobiec wyciekowi ruchu (leak) w momencie zestawiania tunelu, podczas reconnect, lub przy awarii VPN. Implementacja: (1) default policy DROP na OUTPUT i FORWARD, (2) allow tylko ruch do G1 IP:port (UDP 500, UDP 4500 dla IKEv2/NAT-T), (3) allow ruch w ramach established IPsec SA. Kill switch jest aktywowany przy starcie VPN i dezaktywowany dopiero przy celowym wyłączeniu VPN (nie przy awarii — przy awarii kill switch blokuje cały ruch, wymuszając reconnect).

Komponent AC-03: Routing. Terminal kieruje cały ruch (default route) przez tunel IPsec. Split tunneling jest domyślnie zabronione — cały ruch operatora (łącznie z DNS) przechodzi przez tunel. Wyjątek: captive portal detection (potrzebny do podłączenia się do WiFi w hotelu/lotniskowym) — limited bypass z logowaniem. DNS: resolver w Zone 2 (encrypted DNS over IPsec tunnel) — terminal nie kontaktuje external DNS.

Zależności. (1) G1 (Zone 2): terminacja tunelu — single dependency, mitigacja: multiple G1 instances (anycast). (2) PKI (Zone 5): certyfikat klienta — mitigacja: auto-renewal z marginesem (renewal 7 dni przed wygaśnięciem). (3) Sieć fizyczna: WiFi/LTE — poza kontrolą SYLION, mitigacja: kill switch zapobiega wyciekowi.

27.3 Gateway layer — G1, G2, relacja i podział odpowiedzialności

Status: [N] Normatywny Odbiorca: Architekt | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 25.2, 26.2, 27.2, 27.4, 29.3

Gateway layer (Zone 2) stanowi krytyczny punkt kontroli między siecią dostępową (Zone 1) a workloadami operatorów (Zone 3). Składa się z dwóch odrębnych komponentów: G1 i G2.

Komponent GW-01: G1 (Network Gateway). Funkcje: terminacja IPsec IKEv2 (strongSwan responder), firewall stateful L3/L4 (nftables), anti-DDoS (rate limiting, SYN cookies, connection limits per IP), CRL/OCSP check (weryfikacja certyfikatu klienta IPsec), TLS termination (dla management API, jeśli exposed). Architektura: stateless — G1 nie utrzymuje stanu sesji aplikacyjnej. Stan IPsec SA jest utrzymywany w kernel (xfrm state), ale jest efemeryczny i nie jest persistowany. G1 może być restartowany bez wpływu na sesje (reconnect w <5 sekund). Skalowanie: horizontal — multiple G1 instances za load balancerem (L4 LB, np. MetalLB/ECMP), anycast IP. Bezpieczeństwo: minimalna powierzchnia ataku (strongSwan + nftables, brak aplikacji user-space), hardened OS (immutable, read-only roots).

Komponent GW-02: G2 (Application Gateway / Access Broker). Funkcje: Policy Engine (OPA — Open Policy Agent), device posture evaluation (zbiera atrybuty urządzenia: OS version, patch level, encryption status, FIDO2 enrollment), session routing (mapuje operator ID → workload environment w Zone 3), CDR trigger (inicjuje przetwarzanie CDR dla plików przychodzących), attestation verification (dla TEE workloads w STATE/SOVEREIGN), token management (issue/validate/revoke session tokens). Architektura: stateful — G2 utrzymuje cache polityk, stan sesji (active sessions, token lifecycle), device posture history. Stan jest persistowany w backend (Redis/etcd) z replication. G2 jest krytycznym SPOF — mitigacja: active/standby HA, session state replication, graceful failover (<5s). Skalowanie: vertical (single instance per tenant cluster) + HA (active/standby).

Relacja G1 → G2. G1 deszyfruje transport IPsec i przekazuje ruch do G2 przez wewnętrzne połączenie (mutual TLS lub IPsec inter-gateway — zależne od deployment). G2 nigdy nie jest bezpośrednio exposed na internet — jedyny dostęp do G2 jest przez G1. Komunikacja G1 → G2: authenticated (mTLS), encrypted (TLS 1.3), rate-limited (per source IP). G2 → G1: response only (G2 nigdy nie inicjuje połączenia do G1).

Podział odpowiedzialności. G1 odpowiada za: transport security (IPsec, firewall). G2 odpowiada za: application security (policy, identity, routing). G1 nie zna tożsamości operatora — zna certyfikat IPsec (identyfikuje terminal). G2 zna tożsamość operatora — weryfikuje OIDC/FIDO2 token. G1 nie podejmuje decyzji o dostępie — G2 podejmuje. G1 może zablokować ruch na poziomie L3/L4 (firewall rules). G2 może zablokować ruch na poziomie aplikacyjnym (policy deny).

27.4 Session layer — session broker, protokoły, tokeny, polityki

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 25.4, 27.3, 27.5, 29.5, 30.2, 31.1, 31.2

Session layer zarządza cyklem życia sesji operatora — od momentu uwierzytelnienia, przez utrzymanie połączenia z workloadami, po zakończenie sesji. Session broker jest centralnym komponentem tej warstwy.

Komponent SL-01: Session Broker. Funkcje: (1) Session establishment — po pozytywnej decyzji Policy Engine (G2), session broker tworzy sesję: generuje session token (JWT, signed by HSM-backed key), mapuje operator ID do workload set (env-matrix, env-browser, etc.), inicjuje/wznawia microVM workloadów. (2) Session maintenance — monitoruje heartbeat (operator terminal → session broker, interval 30s), re-evaluates policy periodically (co 5 minut lub na trigger — np. zmiana device posture), utrzymuje session state (active workloads, token lifecycle, clipboard policy). (3) Session termination — na żądanie operatora (logout), na decyzję administratora (revoke), na timeout (idle timeout: 15 minut default, configurable per policy), na policy violation (device posture drop, failed re-evaluation). Terminacja obejmuje: unieważnienie tokenu, zamknięcie połączenia ze wszystkimi workloadami, opcjonalnie — destroy microVM (configurable: destroy-on-logout vs keep-warm).

Komponent SL-02: Session Tokens. Format: JWT (JSON Web Token). Issuer: session broker (G2). Signing: HMAC-SHA256 (STANDARD) lub RSA/ECDSA signed by HSM (PRO/STATE). Claims: sub (operator ID), iss (session broker), exp (expiration, 1h default), iat (issued at), tenant_id, tier, workload_set (list of allowed workloads), device_id, posture_score. Token refresh: silent refresh 5 minut przed exp, operator nie widzi procesu. Token revocation: tokeny revokowane natychmiast w session broker (revocation list in Redis, propagacja <5s).

Komponent SL-03: Session Protocols. Pixel streaming: Apache Guacamole (RDP/VNC/SSH to workload → HTML5/WebSocket to terminal) lub SPICE (direct SPICE protocol for Firecracker VM → SPICE client on terminal). Audio: Opus codec (48kHz, VBR, 20ms frames), transported over RTP/SRTP in session tunnel. Input: keyboard/mouse events transported over session protocol (Guacamole protocol or SPICE). Clipboard: controlled by session broker — per workload policy (text-only, disabled, or full — configurable per tier).

Komponent SL-04: Session Policies. Polityki sesji definiowane w OPA (Rego language), ewaluowane przez Policy Engine w G2/session broker. Parametry: idle_timeout (15min default), max_session_duration (8h default, configurable), clipboard_policy (per workload, per tier), concurrent_sessions (1 default for STATE, configurable), workload_set (which workloads operator can access), re_evaluation_interval (5min default).

27.5 Workload layer — microVM orchestration, workload lifecycle

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 24.2, 26.3, 26.4, 27.4, 29.5, 29.6

Workload layer (Zone 3) jest sercem operacyjnym SYLION — tutaj działają środowiska operatorów. Każdy workload jest izolowany w dedykowanej microVM Firecracker.

Komponent WL-01: Firecracker Orchestrator. Odpowiada za: lifecycle microVM (create, start, stop, destroy), resource allocation (CPU, RAM per workload per operator), image management (pull signed image, verify, launch), networking (assign network namespace, configure veth pair, apply eBPF policy). Orchestrator działa w Zone 3 management (odrębny od Zone 5 — orchestrator zarządza workloadami, nie platformą). Orchestrator komunikuje się z session broker (G2) przez authenticated API: session broker → orchestrator: „uruchom env-matrix dla operatora X”, orchestrator → session broker: „env-matrix ready, endpoint: 10.3.X.Y:5900”.

Komponent WL-02: MicroVM Image Registry. Prywatny registry obrazów microVM (OCI-compatible). Obrazy: Alpine-based minimal (env-browser, env-office), NixOS-based (env-matrix, env-signal), custom (env-crm, env-voice). Każdy obraz: podpisany (Cosign), zeskanowany (Trivy — zero critical/high CVE policy), pinned by digest (nie by tag). Obrazy przechowywane w Zone 4 (shared service), pulled by orchestrator w Zone 3 przy starcie microVM.

Workload lifecycle. (1) Provisioning: operator onboarding → IaC tworzy operator namespace w Zone 3, pre-pulls images, pre-configures network. (2) Session start: session broker → orchestrator: start workloads. Orchestrator: tworzy microVM (Firecracker API), boot <150ms, configures network, waits for health check. (3) Running: microVM działa, operator interacts via session protocol. Heartbeat: orchestrator ↔ session broker (30s). Resource monitoring: CPU/RAM per microVM. (4) Session end: session broker → orchestrator: stop workloads. Orchestrator: sends ACPI shutdown to microVM, waits 10s, force-kills if not stopped. (5) Cleanup: ephemeral storage wiped (cryptographic erase — overwrite encryption key), network namespace destroyed, resource freed. (6) Destroy: operator offboarding → orchestrator destroys all operator resources (microVM images cached, but operator-specific state destroyed).

Workload types. env-matrix: Matrix client (Element Web/Desktop) + local Dendrite/Conduit instance (per tenant homeserver). env-browser: Chromium (headless mode + remote display). env-office: LibreOffice (headless + remote display). env-signal: Signal Desktop (isolated, dedicated egress). env-crm: SuiteCRM/Odoo (web app + database). env-voice: Jitsi/LiveKit media server component (per tenant). Każdy workload type ma zdefiniowany resource profile (CPU, RAM, storage, network policy) i security profile (egress policy, clipboard policy, DLP policy).

27.6 Shared services — API, CDR, logi, AI, backup

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra Wpływ na baseline: Wysoki Powiązane rozdziały: 17.4, 17.5, 24.2, 26.10, 27.5, 27.7, 30.5

Shared services (Zone 4) to usługi współdzielone między operatorami, ale z izolacją na poziomie danych (per-tenant/per-operator separation w każdej usłudze).

Komponent SS-01: API Gateway. Reverse proxy (Kong/Envoy) dla Management API i Integration API. Funkcje: rate limiting (per tenant, per API key), authentication (OAuth 2.0 token validation), routing (request → backend service), request/response logging. API Gateway jest entry point dla: Admin Portal → Management API, External SIEM → Log Export API, Customer automation → Provisioning API. Bezpieczeństwo: mTLS (wymagane dla API from Zone 5), OAuth 2.0 (wymagane dla API from external), WAF (basic — SQL injection, XSS protection).

Komponent SS-02: CDR Engine. Przetwarzanie CDR (Content Disarm and Reconstruction) — patrz 26.10 szczegółowy opis. CDR engine w Zone 4 składa się z: CDR orchestrator (przyjmuje request z G2/workload, tworzy efemeryczną microVM CDR, monitoruje processing), CDR microVM fleet (pool of pre-warmed microVMs dla szybkiego przetwarzania), CDR staging storage (encrypted temporary storage dla plików in-flight), CDR quarantine storage (encrypted long-term storage dla oryginalnych plików pre-CDR). Wydajność: target <30s per file (up to 50MB), <60s per file (up to 100MB). Throughput: 100 files/minute per cluster (scalable).

Komponent SS-03: Log Pipeline. Zbieranie i transport logów: agents (Fluent Bit on each host/microVM) → aggregator (Fluentd/Vector in Zone 4) → SIEM ingest (Wazuh/Elastic in Zone 4 for internal SIEM) + SIEM export (to customer SIEM per 25.5 EXT-02). Format: JSON structured logs (RFC 5424 compliant for syslog export). Retention: 12 months (STANDARD), 3 years (PRO), 7 years (STATE/SOVEREIGN). Integrity: append-only log store, hash chain (each entry includes hash of previous entry — tamper detection).

Komponent SS-04: AI Services (eksperymentalny). LLM hostowany lokalnie (Llama/Mistral) do analizy zdarzeń bezpieczeństwa (FN-X01). Deployment: dedicated microVM w Zone 4, GPU-accelerated (A10/L4). Input: wyłącznie metadane zdarzeń (nie treść sesji). Output: sugestie dla SOC analyst. Status: [E] Eksperymentalny.

Komponent SS-05: Backup Service. Narzędzie: Restic z encrypted backend (S3-compatible storage). Zakres: konfiguracja Terraform state, polityki OPA, Keycloak realm config, certyfikaty publiczne. Nie obejmuje: kluczy prywatnych HSM (nie opuszczają HSM), danych sesji operatorów (efemeryczne), treści komunikacji (E2E encrypted, klucze w workloadach). Schedule: daily incremental, weekly full. Retention: 30 days rolling + monthly snapshots 12 months. Test restore: automatyczny, monthly (restore to isolated environment, verify integrity).

Komponent SS-06: Egress Proxy. Proxy dla ruchu wychodzącego z Zone 3 do internetu. Osobne instancje: browser egress proxy (env-browser → internet, URL filtering), Signal egress proxy (env-signal → Signal servers), Matrix federation egress (env-matrix → approved federated homeservers). Każdy egress proxy: TLS inspection (opcjonalnie per policy), URL/domain filtering (allowlist/denylist), bandwidth limiting, logging (URL, timestamp, operator ID, bytes transferred).

27.7 Management plane — bastion, IaC, secrets, SIEM

Status: [N] Normatywny Odbiorca: Architekt | Infra | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.4, 25.2, 26.9, 27.8, 27.9, 30.5

Management plane (Zone 5) jest najsilniej chronionym segmentem infrastruktury SYLION. Zone 5 zarządza całą platformą — kompromitacja Zone 5 oznacza pełną kompromitację systemu.

Komponent MP-01: Bastion Host. Jedyne punkty dostępu do Zone 5. Wymagania: FIDO2 authentication (mandatory), SSH with certificate-based auth (no password, no SSH keys — certificate from Vault CA, 1h lifetime), session recording (all bastion sessions recorded for forensic), audit trail (all commands logged to immutable log store). Bastion jest dostępny wyłącznie z dedykowanego VPN administracyjnego (osobny tunel IPsec, osobny G1 endpoint) lub z fizycznej sieci management (on-premise). Bastion nie jest dostępny z Zone 0 (terminal operatora), Zone 3 (workloady) ani z internetu.

Komponent MP-02: IaC Engine (Terraform + Ansible). Terraform: zarządza infrastrukturą (serwery, sieci, storage, DNS, firewall rules). Ansible: zarządza konfiguracją (OS hardening, package installation, service configuration). Workflow: Git PR → peer review → CI (terraform plan, ansible -check) → approval → apply. State: Terraform state w encrypted S3-compatible backend (minio/S3), locked during apply (state locking via DynamoDB/PostgreSQL). Secrets in IaC: nigdy w plaintext — referenced from Vault/SOPS, injected at apply time.

Komponent MP-03: Secrets Manager (OpenBao lub HashiCorp Vault). HashiCorp Vault: przechowuje i zarządza secrets (API keys, database credentials, certificates, encryption keys). Backend: HSM (for master key — Vault auto-unseal with HSM). Policies: RBAC (Vault policies define who can read/write which secrets). Audit: all Vault operations logged (audit backend → log pipeline). PKI engine: Vault CA issues short-lived certificates for mTLS, SSH, workload identity. Secrets rotation: automated (via Vault dynamic secrets) or policy-driven (rotation schedule per secret type).

UWAGA BSL: HashiCorp zmienił licencję Vault na Business Source License (BSL) w sierpniu 2023, co stworzyło ryzyko prawne dla wdrożeń komercyjnych. Rekomendowane jest użycie OpenBao (fork Vault z licencją MPL 2.0, aktywnie rozwijany przez społeczność) jako drop-in replacement. API jest w pełni kompatybilne. OpenBao stosowany we wszystkich nowych wdrożeniach SYLION.

Komponent MP-04: SIEM Control (Wazuh/Elastic). Internal SIEM: receives all security events from Zone 0–5. Functions: event correlation, rule-based alerting, dashboard/visualization, incident management. SIEM control plane (rules, dashboards, configurations) w Zone 5. SIEM data plane (event storage, search, alerting) w Zone 4 (SS-03). Separation: SIEM admin (Zone 5) can modify rules/alerts, SIEM data (Zone 4) stores events — compromise of Zone 4 data doesn't allow modification of detection rules in Zone 5.

Komponent MP-05: Automation Engine. Automated responses: SIEM alert → automation engine → action (e.g., revoke session, quarantine host, trigger rebuild). Narzędzia: StackStorm/n8n (workflow automation), custom scripts (Python/Go). Safeguards: destructive actions require dual approval (two-person rule) or pre-approved playbook (SOC-approved runbook). All actions logged and auditable.

27.8 Security services — policy engine, attestation, FIDO2, HSM

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 24.4, 26.7, 26.8, 27.4, 27.9, 30.3, 30.6

Security services to zbiór usług odpowiedzialnych za egzekucję polityk bezpieczeństwa, weryfikację tożsamości sprzętowej i zarządzanie materiałem kryptograficznym.

Komponent SEC-01: Policy Engine (OPA). Open Policy Agent — silnik ewaluacji polityk. Deployment: sidecar w G2 (low-latency evaluation), standalone w Zone 5 (policy management, testing). Język polityk: Rego. Polityki: RBAC (role-based), ABAC (attribute-based: czas, lokalizacja, device posture), PBAC (policy-based: combined evaluation). Input: operator identity, device posture, requested resource, context (time, source IP, risk score). Output: allow/deny + reasons + obligations (e.g., „allow but enable session recording”). Latencja: <10ms per evaluation (target), <50ms P99. Polityki wersjonowane w Git, deployed via GitOps. Change log: every policy change = commit in Git + audit event in SIEM.

Komponent SEC-02: Attestation Service. Remote attestation dla workloadów w TEE (AMD SEV-SNP / Intel TDX). Funkcja: weryfikacja, że microVM booted z expected image (measurement: firmware hash + kernel hash + rootfs hash). Flow: (1) microVM boots → hardware generates attestation report (signed by CPU root of trust), (2) report sent to G2/attestation service, (3) attestation service verifies signature (against AMD/Intel root key) and measurement (against expected value from image registry), (4) accept (session allowed) or reject (session blocked, alert). Tier: wymagane dla STATE/SOVEREIGN, opcjonalnie dla PRO, nie dostępne dla STANDARD. Update flow: new image → new expected measurement → update attestation policy → deploy.

Komponent SEC-03: FIDO2 Service. WebAuthn/FIDO2 relying party integrowany z Keycloak. Obsługiwane klucze: YubiKey 5 NFC, YubiKey 5C, Google Titan Security Key, Feitian BioPass. Modes: second factor (password + FIDO2 key), passwordless (FIDO2 only, resident credential). Enrollment: per operator, minimum 2 klucze (primary + recovery). Revocation: immediate (remove credential from Keycloak, propagacja <5s). Tier requirements: STATE/SOVEREIGN — FIDO2 mandatory; PRO — FIDO2 strongly recommended; STANDARD — FIDO2 optional.

Komponent SEC-04: HSM Integration. Interface: PKCS#11 (standard API for HSM). Operations routed to HSM: root CA key operations (sign, never export), intermediate CA key operations (sign), policy signing (signed policy bundles), Vault master key (auto-unseal). HSM types: on-premise (Thales Luna, nCipher, Utimaco), cloud (AWS CloudHSM, Azure Dedicated HSM), software (SoftHSM2 — for STANDARD tier only). HA: HSM in HA cluster (active/standby) with synchronous replication. Monitoring: HSM health check (PKCS#11 probe), tamper detection (physical), key usage counters.

27.9 Identity and policy services — IAM, IdP, RBAC/ABAC/PBAC

Status: [N] Normatywny Odbiorca: Architekt | Dev | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.5, 24.2, 25.4, 27.4, 27.8, 30.3

Identity and policy services zarządzają tożsamością operatorów, ról, atrybutów i polityk dostępu. IAM stanowi fundament modelu Zero Trust — bez zweryfikowanej tożsamości nie ma dostępu.

Komponent ID-01: Keycloak (IAM/IdP). Centralny system zarządzania tożsamością. Deployment: Zone 5 (management plane). Functions: user management (CRUD operators), realm management (per tenant), authentication flows (OIDC, SAML, FIDO2), identity brokering (federation z external IdP), token issuance (access tokens, ID tokens, refresh tokens). Configuration: per tenant realm (każdy tenant ma izolowany realm z własnymi users, roles, policies). HA: Keycloak in cluster (Infinispan cache replication), behind internal load balancer. Database: PostgreSQL (encrypted, per-realm schema isolation).

Komponent ID-02: Role Model (RBAC). Role predefiniowane: OPERATOR (access workloads), TENANT_ADMIN (manage operators, policies in tenant), PLATFORM_ADMIN (manage infrastructure), AUDITOR (read-only logs, reports), SOC_ANALYST (view alerts, manage incidents). Role hierarchy: PLATFORM_ADMIN > TENANT_ADMIN > OPERATOR. Role assignment: per user, per tenant. Role separation: TENANT_ADMIN nie może eskalować do PLATFORM_ADMIN; OPERATOR nie może eskalować do TENANT_ADMIN. Enforcement: Keycloak role mapping → JWT claims → Policy Engine evaluation.

Komponent ID-03: Attribute Model (ABAC). Atrybuty: device_posture_score (0–100, computed by G2), time_of_day (business hours vs off-hours), source_network (corporate VPN vs public WiFi vs mobile), risk_score (computed by SIEM/AI, 0–100), classification_clearance (UNRESTRICTED, INTERNAL, CONFIDENTIAL, SECRET, TOP_SECRET — STATE/SOVEREIGN only). Atrybuty dynamiczne: reevaluated per session (device_posture), per request (time), per event (risk_score). Atrybuty statyczne: assigned per user (classification_clearance), per tenant (tier).

Komponent ID-04: Policy Model (PBAC). Policy-Based Access Control: polityki łączą RBAC (rola) + ABAC (atrybuty) w ujednolicony model decyzyjny. Przykładowa polityka (Rego): „allow if role == OPERATOR AND device_posture_score >= 70 AND time_of_day IN business_hours AND risk_score < 80”. Polityki definiowane per tenant (TENANT_ADMIN), per tier (platform defaults), per workload type. Conflict resolution: deny overrides allow (jeśli jakakolwiek polityka deny — access denied). Audit: każda decyzja polityki logowana (input, output, policy version, evaluation time).

Komponent ID-05: Directory Synchronization. Opcjonalna synchronizacja z katalogiem klienta (AD/LDAP). Direction: pull-only (SYLION pulls user/group data from customer directory). Frequency: configurable (15min default). Scope: configurable (specific OU/group). Privacy: SYLION stores minimum necessary attributes (name/pseudonym, email, group membership, role mapping). Deprovisioning: user deleted/disabled in customer directory → automatic deprovisioning in SYLION (session revoke, workload destroy, identity archive).

27.10 Integrations layer — external IdP, SIEM export, API connectors

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner | Klient Wpływ na baseline: Średni Powiązane rozdziały: 17.5, 24.3, 25.5, 27.6, 31.8

Warstwa integracji zapewnia kontrolowaną komunikację SYLION z systemami zewnętrznymi klienta. Wszystkie integracje przechodzą przez zdefiniowane punkty w Zone 4 (data plane integracji) lub Zone 5 (control plane integracji).

INT-01: External IdP Integration. Protokoły: OIDC (OpenID Connect 1.0), SAML 2.0. Konfiguracja: per tenant w Keycloak (Zone 5). Obsługiwane IdP: Azure AD, Okta, Google Workspace IdP, Keycloak (zewnętrzny), ADFS, Ping Identity, OneLogin. Konfiguracja: (1) admin tenanta rejestruje IdP (client_id, client_secret, discovery URL), (2) Keycloak konfiguruje realm z identity broker, (3) testowe logowanie, (4) aktywacja. Bezpieczeństwo: backchannel logout (wymagany), token encryption (opcjonalny), PKCE (wymagany dla OIDC).

INT-02: SIEM Export. Protokoły: CEF over syslog (TCP/TLS), JSON over syslog (RFC 5424, TCP/TLS), Splunk HEC (HTTPS), Azure Sentinel Data Connector (HTTPS), QRadar Log Source (syslog). Konfiguracja: per tenant (admin tenanta definiuje endpoint, format, kategorie zdarzeń). Filtrowanie: admin tenanta wybiera kategorie (session events, policy decisions, CDR events, admin operations, infrastructure alerts). Buforowanie: Zone 4 bufor 72h — zdarzenia retransmitowane po przywróceniu łączności z SIEM klienta. Bezpieczeństwo: transport szyfrowany (TLS 1.3), uwierzytelnianie (certificate-based lub token-based), dedykowane credentiala per tenant.

INT-03: API Management. REST API dla automatyzacji klienta: provisioning operatorów, zarządzanie politykami, monitoring statusu, eksport raportów. Wersjonowanie: URL path (/v1/, /v2/). Uwierzytelnianie: OAuth 2.0 (client credentials flow dla automatyzacji, authorization code flow dla interakcji administracyjnych) + mTLS. Rate limiting: per tenant, per API key. Documentation: OpenAPI 3.1 spec, Swagger UI (dostępny tylko z portalu administracyjnego). SDK: Python, Go (oficjalne), community-contributed dla Node.js, Java.

INT-04: Webhook Notifications. SYLION wysyła powiadomienia webhook do zdefiniowanych endpointów klienta: incydenty, wygasające certyfikaty, provisioning complete, offboarding complete. Format: JSON, schema zdefiniowany per event type. Bezpieczeństwo: HMAC signature (SHA-256) na payload, retry (3x z backoff), dead letter queue (po 3 failures → alert).

INT-05: MDM Integration. Opcjonalna integracja z MDM klienta (Intune, Jamf, Mosyle). Direction: SYLION → MDM (odczyt device compliance status), MDM → SYLION (webhook on compliance change). Integracja pozwala G2 na uwzględnienie compliance score MDM w device posture evaluation.

27.11 Data layer — storage per workload, log storage, backup, CDR staging

Status: [N] Normatywny Odbiorca: Architekt | Infra | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 17.4, 26.3, 27.5, 27.6, 30.10

Warstwa danych SYLION jest rozproszona między Zone 3 (storage per-operator), Zone 4 (logi, CDR staging, backup) i Zone 5 (Terraform state, secrets, configuration). Nie istnieje centralny „data store” — dane są rozproszone zgodnie z zasadą least privilege i per-operator isolation.

DL-01: Workload Storage (Zone 3). Każdy workload operatora ma dedykowany ephemeral storage: (1) rootfs — read-only (obraz microVM, shared via copy-on-write), (2) overlay — read-write (dane sesji, temporary files, application state), (3) persistent volume (opcjonalny) — encrypted block device per operator (LUKS2 + dm-crypt, key derived from HSM). Persistent volume: używany dla env-office (dokumenty robocze), env-crm (database), env-matrix (local message cache). Persistent volume jest encrypted-at-rest (AES-256) i encrypted-in-transit (mTLS do storage backend). Lifecycle: persistent volume tworzony przy provisioning operatora, zniszczony (cryptographic erase — key destruction) przy offboarding.

DL-02: Log Storage (Zone 4). Logi bezpieczeństwa: append-only store (Wazuh/Elasticsearch z immutable index policy). Logi operacyjne: Loki (application logs, performance logs). Format: JSON structured. Retention: 12 months (STANDARD), 3 years (PRO), 7 years (STATE/SOVEREIGN). Integrity: hash chain (każdy log entry

zawiera hash poprzedniego — tamper detection), periodic integrity verification (daily job sprawdza chain continuity). Encryption: at-rest (AES-256), access-controlled (RBAC — SOC_ANALYST can search, AUDITOR can export, OPERATOR cannot access). Isolation: per-tenant index (tenant A nie widzi logów tenant B).

DL-03: Backup Storage (Zone 4). Encrypted backup (Restic + S3-compatible backend). Content: Terraform state, OPA policies, Keycloak realm export, certificate metadata (not private keys). Not backed up: HSM keys (never leave HSM), workload ephemeral data, session content. Encryption: Restic encryption (AES-256-CTR + Poly1305) + storage-level encryption. Retention: 30 days rolling + 12 monthly snapshots. Geographic: primary region + secondary region (for DR). Access: PLATFORM_ADMIN only, dual approval for restore.

DL-04: CDR Staging (Zone 4). Temporary storage dla plików w pipeline CDR. Lifecycle: file uploaded → staged (encrypted at rest) → CDR processed → delivered or quarantined → staging cleaned (max 1h retention in staging). Quarantine storage: separate, longer retention (30 days default, configurable per policy), for forensic analysis of rejected files. Encryption: AES-256, per-file key (derived from HSM, destroyed after delivery/quarantine).

DL-05: Configuration Storage (Zone 5). Terraform state: encrypted S3-compatible backend, versioned, locked during apply. Vault secrets: encrypted backend (HSM-backed master key). Keycloak database: PostgreSQL, encrypted, per-realm isolation. Git repositories: IaC code, policy code, image definitions — stored in self-hosted GitLab (Zone 5), encrypted at rest, access-controlled.

27.12 Dependencies map — critical path analysis, single points of failure, mitigation

Status: [N] Normatywny Odbiorca: Architekt | Infra | SOC | Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 24.1, 27.1–27.11, 28.9, 29.8

Mapa zależności identyfikuje krytyczne ścieżki i potencjalne single points of failure (SPOF) w architekturze SYLION, wraz z mechanizmami mitygacji.

Ścieżka krytyczna 1: Operator Login. Terminal → (sieć fizyczna) → G1 → G2 → Policy Engine → Session Broker → Orchestrator → Workload. SPOF: G1 (mitigacja: multiple instances, anycast), G2 (mitigacja: active/standby HA), Policy Engine (mitigacja: sidecar w G2, local cache), Session Broker (mitigacja: state replication, graceful failover). Krytyczność: jeśli login path jest niedostępny, żaden operator nie może rozpocząć sesji. Target availability: 99,95% per component.

Ścieżka krytyczna 2: Session Maintenance. Terminal ↔ (tunel IPsec) ↔ G1 → G2/Session Broker ↔ Workload. SPOF: tunel IPsec (mitigacja: auto-reconnect, multiple G1 instances), Session Broker (mitigacja: session state replication — jeśli broker fails, standby przejmuje sessions). Krytyczność: awaria session maintenance = utrata aktywnych sesji. Target: session survival through single component failure.

Ścieżka krytyczna 3: File Transfer (CDR). Workload → CDR request → G2/CDR trigger → CDR orchestrator (Zone 4) → CDR microVM → Workload. SPOF: CDR orchestrator (mitigacja: redundant orchestrator instances), CDR microVM fleet (mitigacja: pre-warmed pool, auto-scaling). Krytyczność: awaria CDR = blokada transferu plików (ale nie blokada sesji).

Ścieżka krytyczna 4: PKI/HSM. Wszystkie certyfikaty i klucze pochodzą z HSM → Vault PKI → komponenty. SPOF: HSM (mitigacja: HA cluster, offline backup procedure for root key ceremony), Vault (mitigacja: HA cluster, auto-unseal with HSM). Krytyczność: awaria HSM/Vault = brak możliwości wystawienia nowych certyfikatów. Mitigacja: certyfikaty mają lifetime (24h–30 dni) — krótkoterminowa awaria HSM nie wpływa na istniejące sesje.

Single Points of Failure — podsumowanie.

												Komponent	SPOF Risk	Mitigation
												G1	Medium	Multiple instances, anycast
												G2	High	Active/standby HA
												Session Broker	High	State replication, failover
												Policy Engine (OPA)	Low	Sidecar, local cache
												HSM	Critical	HA cluster, ceremony backup
												Vault	High	HA cluster, HSM unseal
												Keycloak	High	Cluster, DB replication
												CDR Orchestrator	Medium	Redundant instances
												Log Pipeline	Low	Buffer, retry, multi-path
												IaaS Provider	Medium	Multi-cloud, DR region
												DNS	Medium	Multi-provider, DNSSEC
												NTP	Low	Multiple sources, NTS

Żaden pojedynczy komponent — poza HSM w wariacie z jednym urządzeniem — nie powinien stanowić nieskorygowanego SPOF. Architektura zakłada, że każdy komponent może ulec awarii, i definiuje mechanizm failover/rebuild dla każdego.

Rozdział 28. Tryby pracy i modele wdrożenia

28.1 Cloud managed (SYLION-operated) — pełna usługa zarządzana

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Partner | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.1, 24.1, 25.6, 27.7, 28.2, 28.9

Cloud managed to domyślny i najprostszy model wdrożenia SYLION. Klient subskrybuje usługę — SYLION Sp. z o.o. odpowiada za pełne wdrożenie, utrzymanie, aktualizacje, monitoring i wsparcie. Klient nie zarządza infrastrukturą.

Architektura. Infrastruktura SYLION działa na wybranych dostawcach IaaS (Hetzner, OVH, AWS, Azure — wybór zależny od regionu i wymagań klienta). Wszystkie strefy (Zone 1–5) zarządzane przez SYLION. Klient dostępuje system wyłącznie jako operator (Zone 0 → Zone 3) lub jako administrator tenanta (Admin Portal w Zone 5).

Odpowiedzialność. SYLION: provisioning infrastruktury, patching, monitoring 24/7, incident response, DR, backup, aktualizacje komponentów, zarządzanie HSM (cloud-hosted), zarządzanie PKI, wsparcie L2/L3. Klient: provisioning operatorów (przez Admin Portal/API), definiowanie polityk (w ramach dozwolonych opcji per tier), zarządzanie integracjami (IdP, SIEM), szkolenie operatorów, zgłaszanie incydentów.

Tiery. STANDARD (400€/op/month): infrastruktura współdzielona (multi-tenant na poziomie compute, per-tenant isolation na poziomie workload/network/crypto), cloud KMS (software HSM equivalent), SLA 99,95%. PRO (1500€/op/month): dedicated compute per tenant cluster, cloud dedicated HSM, SLA 99,97%, extended audit, BYOK option. STATE/SOVEREIGN: nie dostępne w modelu cloud managed (wymaga sovereign cloud lub on-premise).

Onboarding flow. (1) Umowa + SLA → (2) provisioning tenant (IaC, 2h) → (3) konfiguracja integracji (IdP, SIEM, 1–4h) → (4) onboarding operatorów (enrollment FIDO2, terminal setup, 1–2h per batch) → (5) testy akceptacyjne → (6) go-live. Total: 1–3 dni robocze.

Ograniczenia. Klient nie ma dostępu do infrastruktury (Zone 5), nie może modyfikować konfiguracji sieci, nie może instalować custom software poza zdefiniowanymi workloadami. Klient nie kontroluje lokalizacji danych (SYLION wybiera region) — chyba że umowa definiuje region constraint (np. „EU only”). Klient deleguje zaufanie SYLION w zakresie operacji infrastrukturalnych.

28.2 Sovereign cloud (customer cloud account, SYLION software) — hybryda

Status: [N] Normatywny Odbiorca: Zarząd | Architekt | Compliance | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.1, 24.4, 25.6, 28.1, 28.3

Model sovereign cloud to hybryda: infrastruktura działa na koncie chmurowym klienta (AWS, Azure, GCP, OVH), ale oprogramowanie pochodzi od SYLION. Klient kontroluje infrastrukturę, SYLION dostarcza oprogramowanie i opcjonalne wsparcie operacyjne.

Architektura. Klient zakłada konto u dostawcy IaaS w wybranej jurysdykcji. SYLION dostarcza moduły Terraform + Ansible roles + container/microVM images. Klient (lub partner wdrożeniowy) wdraża infrastrukturę za pomocą IaC. Klient zarządza Zone 5 (management) — ma pełny dostęp do bastionu, IaC, secrets, SIEM control. SYLION może mieć ograniczony dostęp (opcjonalny) do Zone 5 dla wsparcia L3 — ale tylko za jawną zgodą klienta, z audit trail.

Odpowiedzialność. Klient: infrastruktura (serwery, sieć, storage), zarządzanie HSM (cloud dedicated lub on-premise), zarządzanie PKI (z pomocą SYLION procedures), monitoring (z pomocą SYLION dashboardów), patching (z pomocą SYLION update pipeline), DR (z pomocą SYLION procedures). SYLION: dostarczenie oprogramowania (signed images, Terraform modules, Ansible roles), aktualizacje (nowe wersje, security patches — dostarczane jako nowe obrazy/moduły), wsparcie L2/L3 (remote, per umowę), documentation (procedury operacyjne, runbooki).

Tiery. PRO (1500€/op/month — software license): wszystkie funkcje PRO, infrastruktura klienta. STATE/SOVEREIGN (2500€/op/month, min 50 ops): wszystkie funkcje sovereign, dedicated HSM on-premise lub customer-controlled cloud HSM, Confidential Computing, PQC.

Suwerenność. Klient kontroluje: fizyczną lokalizację danych (region/datacenter), klucze kryptograficzne (HSM pod kontrolą klienta), polityki (definiowane i egzekwowane lokalnie), konto dostawcy IaaS (SYLION nie ma dostępu do konta klienta bez jawnej delegacji). Po zakończeniu wdrożenia klient może kontynuować operacje bez SYLION — jedyną zależność to aktualizacje oprogramowania (opcjonalne) i wsparcie (opcjonalne).

Onboarding flow. (1) Umowa + architektura review → (2) klient przygotowuje konto IaaS → (3) SYLION/partner wdraża IaC (1–3 dni) → (4) ceremonia HSM (generowanie root CA key — 1 dzień, jeśli on-premise HSM) → (5) konfiguracja integracji → (6) onboarding operatorów → (7) testy akceptacyjne → (8) go-live. Total: 1–3 tygodnie.

28.3 On-premise sovereign — pełna instalacja na infrastrukturze klienta, wymagania

Status: [N] Normatywny (dla tieru STATE/SOVEREIGN) Odbiorca: Zarząd | Architekt | Infra | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.1, 24.4, 25.6, 28.2, 28.6

On-premise sovereign to najwyższy poziom suwerenności: cała platforma SYLION działa na infrastrukturze fizycznie kontrolowanej przez klienta — w jego datacenter, na jego sprzęcie, zarządzana przez jego personel.

Wymagania sprzętowe (minimum per klaster). Compute: 3x management nodes (Zone 5, 16 vCPU / 64GB RAM / 500GB NVMe each), 2x gateway nodes (Zone 2, G1+G2, 8 vCPU / 32GB RAM each), Nx workload nodes (Zone 3, sizing zależny od liczby operatorów — 1 node per 10–20 operatorów, 32 vCPU / 128GB RAM / 1TB NVMe per node), 1x shared services node (Zone 4, 16 vCPU / 64GB RAM / 2TB NVMe). Networking: 10GbE internal, 1GbE uplink (minimum), redundant switches, out-of-band management (IPMI/iDRAC/iLO). HSM: 1x on-premise HSM (Thales Luna, nCipher, Utimaco — FIPS 140-3 Level 3), HA recommended (2x HSM in cluster). Storage: NVMe for workloads (local), S3-compatible object storage for backups/logs (MinIO on dedicated node or external NAS).

Wymagania software. OS: Flatcar Container Linux lub Talos Linux (immutable, hardened). Orchestration: Kubernetes (k3s/RKE2) lub bare Firecracker (without Kubernetes, lighter weight). Networking: Calico/Cilium (eBPF-based CNI), MetalLB (load balancing). Secrets: HashiCorp Vault (on-premise, HSM-backed). IaC: Terraform + Ansible (delivered by SYLION as modules/roles).

Wymagania operacyjne. Personel: minimum 2 osoby przeszkolone w administracji SYLION (szkolenie zapewnione przez SYLION, 5 dni). Procedury: runbooki dostarczone przez SYLION (patching, monitoring, DR, ceremonia HSM). Monitoring: stack dostarczony (Prometheus + Grafana + Loki), podłączony do SIEM klienta. DR: secondary site (opcjonalnie, ale silnie rekomendowany) — replikacja konfiguracji do secondary, RTO <4h.

Onboarding flow. (1) Architektura review + hardware procurement (2–6 tygodni) → (2) instalacja sprzętu w datacenter klienta → (3) wdrożenie OS (IaC, 1 dzień) → (4) wdrożenie SYLION (IaC, 2–3 dni) → (5) ceremonia HSM (1 dzień) → (6) konfiguracja + testy (2–3 dni) → (7) szkolenie personelu (5 dni) → (8) go-live. Total: 4–10 tygodni.

28.4 Hybrid — control plane managed, data plane on-premise

Status: [R] Rekomendowany Odbiorca: Zarząd | Architekt | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 17.1, 28.1, 28.3, 28.9

Model hybrydowy łączy zalety cloud managed (prostota zarządzania control plane) z wymaganiami suwerenności (dane operatorów on-premise). Control plane (Zone 5: IAM, IaC automation, monitoring, SIEM control) działa w chmurze zarządzanej przez SYLION. Data plane (Zone 2: gateway, Zone 3: workloady, Zone 4: logi lokalne, CDR) działa on-premise u klienta.

Architektura. Control plane (cloud): Keycloak (IAM), Vault (secrets, z HSM integration — cloud lub on-premise HSM z remote access), IaC engine (Terraform apply z cloud do on-premise via secured channel), monitoring (Prometheus federation — on-premise exporters → cloud aggregator), SIEM control (rules, dashboards w cloud, event data on-premise). Data plane (on-premise): G1, G2, workloady operatorów, CDR, log storage, backup.

Połączenie control ↔ data. Dedykowany tunel IPsec (site-to-site) między cloud control plane a on-premise data plane. Ruch: configuration pushes (Terraform → on-premise), telemetry pulls (on-premise → cloud monitoring), IAM queries (on-premise G2 → cloud Keycloak). Ruch operatorski (sesje operatorów) nie przechodzi przez cloud — operator → on-premise G1 → on-premise G2 → on-premise workloady.

Uzasadnienie. Model hybrydowy jest odpowiedni gdy: klient wymaga, aby dane operatorów nigdy nie opuściły jego lokalizacji (regulacyjne), ale nie posiada kompetencji do zarządzania pełnym control plane (IAM, secrets, monitoring). SYLION zarządza control plane — klient kontroluje data plane. Kompromis: dane suwerenne, zarządzanie uproszczone.

Ograniczenia. Zależność od łączności cloud ↔ on-premise: jeśli tunel site-to-site ulegnie awarii, on-premise data plane działa w trybie autonomicznym (sesje utrzymane, polityki cached, logi buforowane) — ale nowe loginy mogą być zablokowane (zależność od Keycloak w cloud). Mitigacja: Keycloak replica on-premise (read-only, sync z cloud), umożliwiając loginy w trybie offline. Latencja: policy evaluation z cloud Keycloak dodaje 20–50ms. Mitigacja: cache w G2.

28.5 Edge / field deployment — mobilne środowisko terenowe, ograniczone zasoby

Status: [R] Rekomendowany Odbiorca: Architekt | Infra | Klient Wpływ na baseline: Średni Powiązane rozdziały: 24.5, 27.1, 28.3, 28.6, 28.8

Edge/field deployment to wariant wdrożenia dla scenariuszy terenowych: operacje polowe, misje humanitarne, stanowiska dowodzenia w lokalizacjach bez stałej infrastruktury IT.

Architektura. Miniaturowy klaster SYLION w formie przenośnej: 1x mini server (Intel NUC lub Lenovo ThinkEdge SE30/SE50 — 8–16 vCPU, 32–64GB RAM, 1TB NVMe) + 1x HSM USB (YubiHSM 2 — FIPS 140-2 Level 3, wystarczający dla ograniczonego PKI) + 1x router (GL.iNet z pre-configured IPsec) + terminale (Pixel + GrapheneOS). Klaster obsługuje 5–15 operatorów jednocześnie.

Uproszczenia względem pełnego wdrożenia. (1) Brak multi-node HA: single server — awaria serwera = utrata usługi (mitigacja: backup na encrypted USB, rebuild <1h). (2) Brak Zone 5 separation: management i workloady na tym samym serwerze (mitigacja: namespace isolation, eBPF). (3) Uprozczone CDR: basic CDR (format validation + metadata stripping, bez pełnej rekonstrukcji). (4) Ograniczone workloady: env-matrix (primary), env-browser (optional), env-voice (if bandwidth allows), env-crm, env-office — nie dostępne w trybie edge (resource constraints).

Łączność. Scenariusze: (a) satellite uplink (Starlink, Iridium) — wysoką latencja (50–600ms), ograniczony bandwidth (10–50 Mbps). (b) LTE/5G modem — zmienna jakość. (c) No connectivity (air-gapped edge) — patrz 28.6. Adaptacja: pixel streaming z adaptacyjnym kodekiem (Opus/VP9, quality adjusts to bandwidth), reduced heartbeat interval (60s instead of 30s), batched telemetry (logs sent in bulk when connectivity available).

Provisioning. Edge kit jest przygotowany w „factory” (biuro SYLION lub klienta): serwer pre-configured, images pre-loaded, keys pre-provisioned (certificates, VPN config, HSM setup). W terenie: podłącz zasilanie + sieć → boot → gotowe w <5 minut. Re-provisioning w terenie: nie zalecane (brak pełnego IaC pipeline) — w razie awarii: rebuild z backup (USB key, encrypted, pre-prepared).

28.6 Air-gapped / restricted network mode — brak internetu, lokalna infrastruktura

Status: [R] Rekomendowany Odbiorca: Architekt | Infra | Compliance | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 17.1, 24.4, 28.3, 28.5

Air-gapped mode to wariant wdrożenia dla środowisk bez łączności z internetem: classified networks, systemy C4ISR, secured facilities. Cała platforma działa w izolowanej sieci, bez żadnego ruchu do/z internetu.

Architektura. Identyczna jak on-premise sovereign (28.3), z następującymi modyfikacjami: (1) Brak egress: env-browser bez dostępu do internetu (tylko intranet klienta, jeśli istnieje), env-signal niedostępny (Signal wymaga internetu), Matrix federation wyłączona (brak federacji z external homeservers). (2) Lokalne repozytorium: images (microVM, container) przechowywane w lokalnym registry (Zone 4), aktualizacje dostarczane offline (encrypted USB/DVD, po weryfikacji podpisu). (3) Lokalne NTP: GPS-based time source lub rubidium/cesium clock, NTP server w Zone 4 synchronizowany lokalnie. (4) Lokalne CA: pełna hierarchia PKI lokalna, brak zależności od zewnętrznych CA (Let's Encrypt, DigiCert). (5) Lokalne DNS: recursive resolver w Zone 4, authoritative DNS w Zone 5.

Aktualizacje offline. Proces: (1) SYLION przygotowuje update bundle (signed, encrypted) → (2) dostarczenie fizyczne (kurier, poczta dyplomatyczna) → (3) admin klienta weryfikuje podpis bundle (Cosign, offline verification) → (4) import do lokalnego registry → (5) apply via IaC (Terraform/Ansible from local repo). Security: bundle signed z kluczem SYLION release (publiczny klucz pre-loaded na HSM klienta), encrypted z kluczem tenanta. Tamper detection: hash chain w bundle manifest.

Ograniczenia. (1) Brak remote support: SYLION nie może zdalnie diagnozować problemów — wsparcie ograniczone do dokumentacji, runbooków i (opcjonalnie) fizycznej wizyty serwisowej. (2) Brak automatycznych aktualizacji: patch latency zależna od procesu fizycznej dostawy. (3) Brak Signal/browser: workloady wymagające internetu niedostępne. (4) Brak external IdP federation: tożsamość zarządzana wyłącznie lokalnie (Keycloak, bez federacji). (5) Brak SIEM export do chmury: logi pozostają on-premise (eksport offline — encrypted media).

28.7 Mobile heavy mode — primary terminal is mobile, desktop secondary

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Klient Wpływ na baseline: Średni Powiązane rozdziały: 17.2, 24.2, 27.1, 28.5

Mobile heavy mode to profil konfiguracyjny, w którym głównym terminalem operatora jest urządzenie mobilne (Pixel + GrapheneOS), a laptop jest opcjonalnym uzupełnieniem. Większość interakcji odbywa się na ekranie telefonu.

Adaptacje UX. (1) Layout mobilny: workloady wyświetlane w trybie pełnoekranowym (full-screen per workload), przełączanie między workloadami gestem lub tab bar. (2) Input: virtual keyboard (z SYLION custom keyboard — nie systemowy, aby ograniczyć keylogging risk), voice input (Opus, speech-to-text w workload, nie na terminalu). (3) Pixel streaming: adaptacyjna rozdzielczość (720p na LTE, 1080p na WiFi), target framerate 30fps (nie 60fps — oszczędność bandwidth i baterii). (4) Notyfikacje: push notifications z session broker → terminal (FCM-less — GrapheneOS UnifiedPush, nie Google FCM, aby uniknąć metadanych Google).

Adaptacje sesji. (1) Aggressive idle timeout: 5 minut na mobile (vs 15 minut na desktop) — telefon częściej pozostawiany bez nadzoru. (2) Biometric re-auth: FIDO2 userVerification=required (biometria Pixel) przy każdym wznowieniu z background. (3) Kill switch enhanced: na mobile kill switch blokuje również WiFi/Bluetooth scanning gdy VPN jest aktywny (GrapheneOS profile). (4) Screen recording detection: opcjonalny — monitoring Android screen capture API, alert jeśli operator próbuje nagrywać ekran (mitigacja ograniczona — DRM-level protection nie jest możliwa na open-source OS).

Workloady mobile-optimized. env-matrix: responsive layout, obsługa gestów, inline media preview. env-voice: primary use case na mobile — rozmowy głosowe. env-browser: usable ale ograniczony (mały ekran, typing difficulty). env-office: nie rekomendowany na mobile (edycja dokumentów na 6" ekranie jest niepraktyczna). env-crm: read-only mode na mobile, edycja na desktop.

28.8 Command center mode — wiele operatorów, jedno fizyczne miejsce, współdzielona infrastruktura sieciowa

Status: [R] Rekomendowany Odbiorca: Architekt | Infra | Klient Wpływ na baseline: Średni Powiązane rozdziały: 25.2, 27.1, 28.3, 28.5

Command center mode to profil wdrożenia dla scenariuszy, w których wielu operatorów pracuje z jednej fizycznej lokalizacji: centrum dowodzenia, sztab kryzysowy, operations room, security operations center.

Architektura sieciowa. Wszyscy operatorzy łączą się z jednej sieci LAN do G1. Konfiguracja: (1) Dedykowana VLAN dla terminali operatorów (izolacja od reszty sieci klienta). (2) Firewall na granicy VLAN → uplink (blokada ruchu non-IPsec, identycznie jak kill switch per terminal, ale na poziomie infrastruktury sieciowej). (3)

Opcjonalnie: G1 on-premise (w tej samej lokalizacji co terminale) — eliminacja latencji WAN, sesja operatora zamyka się w sieci lokalnej. (4) QoS: traffic prioritization — VoIP/real-time sesje > file transfer > telemetry.

Współdzielona infrastruktura. Terminale (Pixel dock + monitor + klawiatura/mysz lub laptopy na docking stations). Sieć: enterprise-grade WiFi (WPA3-Enterprise, 802.1X with RADIUS backed by SYLION PKI) lub Ethernet (preferred — deterministic latency, no radio interference). Audio: headsets per operator (izolacja audio), opcjonalnie: shared audio for briefings (env-voice room with shared speaker).

Security considerations. (1) Physical security: pomieszczenie command center musi spełniać wymagania fizycznego bezpieczeństwa (kontrola dostępu, CCTV, brak okien/RF shielding dla SECRET+). (2) Visual security: monitory ustawione tak, aby osoby nieautoryzowane nie mogły widzieć ekranów (privacy screens, układ pomieszczenia). (3) Shoulder surfing: operator awareness training. (4) Shared terminal risk: w command center terminale mogą być współdzielone (zmiana operatora). Wymaganie: full session cleanup między operatorami (logout → re-login → FIDO2 re-auth). Brak hot-desking bez re-auth.

Skalowanie. Command center mode skaluje się do 50–100 operatorów w jednej lokalizacji (ograniczenie: bandwidth uplink, compute capacity on-premise G1, QoS). Powyżej 100 operatorów: multiple G1 instances (load balanced), potentially multiple workload nodes.

28.9 DR / secondary region mode — failover, replikacja konfiguracji, RTO targets

Status: [N] Normatywny (dla PRO i STATE/SOVEREIGN) Odbiorca: Architekt | Infra | SOC | Zarząd Wpływ na baseline: Krytyczny (PRO, STATE/SOVEREIGN) Powiązane rozdziały: 17.4, 24.1, 27.12, 28.1, 28.2, 29.8

DR (Disaster Recovery) / secondary region mode zapewnia ciągłość działania w przypadku utraty primary region (awaria datacenter, katastrofa naturalna, atak).

Architektura DR. Primary region: pełna platforma SYLION (Zone 1–5). Secondary region: standby infrastructure — pre-provisioned (laC applied, bare compute ready), ale bez aktywnych workloadów. Replikacja: konfiguracja (Terraform state, OPA policies, Keycloak realm export, certificate metadata) replikowana do secondary co 15 minut (async). Dane sesji operatorów: nie replikowane (efemeryczne — operatorzy re-login po failover). Logi: replikowane do secondary (async, RPO <1h). HSM state: nie replikowany automatycznie (HSM keys: backup via ceremony — patrz 26.8; DR HSM initialized from backup during failover).

Failover flow. (1) Detection: monitoring wykrywa utratę primary (health checks, external probes — <5min detection). (2) Decision: automated failover (PRO) lub manual decision (STATE/SOVEREIGN — wymaga approval PLATFORM_ADMIN). (3) Activation: secondary laC applied (terraform apply with DR state — <30 min), DNS failover (update A/AAAA records for G1 to secondary IP — TTL 60s, propagation <5min). (4) HSM activation: DR HSM initialized from backup (if on-premise: physical ceremony required — adds time; if cloud: automated). (5) Keycloak restored: realm imported, operators can login. (6) Workloads: operators login, session broker creates new workloads on secondary compute. (7) Verification: smoke tests, operator acceptance.

RTO targets. STANDARD: RTO <4h (manual failover, pełna procedura). PRO: RTO <1h (semi-automated failover, pre-provisioned secondary). STATE/SOVEREIGN: RTO <1h (pre-provisioned, HSM backup ready, rehearsed procedure). RPO: konfiguracja <15 min, logi <1h, dane sesji: 0 (efemeryczne, nie replikowane — operator re-creates state po failover).

Testowanie DR. Wymagane: quarterly DR test (failover to secondary, verify operator login, verify workload availability, verify log pipeline). Dokumentacja: każdy test generuje DR Test Report (timestamp, steps executed, issues found, RTO achieved, remediation plan). DR test nie powinien wpływać na produkcję (test w izolowanym namespace lub po godzinach z controlled switchover).

Multi-region active/active (future). Architektura active/active (oba regiony obsługują operatorów jednocześnie) jest planowana, ale nie zaimplementowana.

Wymaga: session state replication (low-latency, cross-region), consistent policy evaluation, conflict resolution. Status: [E] Eksperymentalny — planowana analiza Q1 2027.

Rozdział 29. Wzorce architektoniczne i antywzorce

29.1 Wzorce przyjęte — lista z uzasadnieniem

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 26.1–26.12, 27.1–27.12, 29.2–29.10

Architektura SYLION jest zbudowana na zbiorze wzorców architektonicznych, z których każdy adresuje konkretne wymaganie bezpieczeństwa, niezawodności lub skalowalności. Wzorce te są normatywne — ich pominięcie wymaga udokumentowanego uzasadnienia z akceptacją Security Architecta.

PAT-01: Zero Trust Network Access (ZTNA). Uzasadnienie: eliminacja implicit trust — żaden komponent nie jest zaufany domyślnie, każdy dostęp wymaga weryfikacji tożsamości, device posture i polityki. Implementacja: G2 Policy Engine (OPA), continuous re-evaluation, no VPN = no access.

PAT-02: Micro-segmentation. Uzasadnienie: ograniczenie blast radius — kompromitacja jednego operatora nie wpływa na innych. Implementacja: per-operator network namespace (Zone 3), eBPF/nftables enforcement, no lateral traffic.

PAT-03: Immutable Infrastructure. Uzasadnienie: eliminacja drift, deterministic state, forensic-ready (known-good state). Implementacja: GitOps, image pinning, no SSH (poza break-glass), rebuild-first.

PAT-04: Sidecar Proxy. Uzasadnienie: transparent security enforcement bez modyfikacji aplikacji. Implementacja: Envoy sidecar w workloadach Zone 3 (mTLS termination, policy enforcement, observability) — opcjonalnie, where Kubernetes is used.

PAT-05: Policy-as-Code. Uzasadnienie: polityki wersjonowane, testowalne, audytowalne, reproducibile. Implementacja: OPA/Rego, Git-managed, CI-tested, deployed via GitOps.

PAT-06: Circuit Breaker. Uzasadnienie: zapobieganie cascade failures — jeśli downstream service jest nieosiągalny, circuit breaker szybko failuje zamiast blokować calling service. Implementacja: circuit breaker na komunikacji G2 → Zone 4 services (CDR, SIEM export, API gateway). Open/half-open/closed states, configurable thresholds.

PAT-07: Bulkhead. Uzasadnienie: izolacja zasobów — awaria jednego tenanta nie zużywa zasobów innego. Implementacja: resource quotas per tenant (CPU, RAM, storage, bandwidth), namespace isolation, rate limiting per tenant.

PAT-08: Saga for Provisioning. Uzasadnienie: provisioning operatora obejmuje wiele kroków (IAM, VPN, workloads, policies) — saga zapewnia consistency i compensating transactions przy failure. Implementacja: orchestrated saga (provisioning engine koordynuje kroki, rollback przy failure).

29.2 Wzorce zakazane — co jest architektonicznie zabronione i dlaczego

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 24.6, 26.13, 29.1, 29.10

Wzorce zakazane to architektoniczne i operacyjne praktyki, które są bezwzględnie zabronione w SYLION. Naruszenie dowolnego zakazu jest traktowane jako incydent architektoniczny wymagający natychmiastowej korekty.

BAN-01: Implicit Trust. Zakazane: jakiegokolwiek komponent ufa innemu bez weryfikacji (np. „ten serwer jest w naszej sieci, więc jest zaufany”). Każdy dostęp wymaga explicit verification (tożsamość, polityka, device state).

BAN-02: Shared Secrets between Tenants. Zakazane: współdzielenie kluczy kryptograficznych, certyfikatów, credentials między tenantami. Każdy tenant ma odrębne klucze, odrębne certyfikaty, odrębne credentiale. Wyjątek: infrastrukturalne TLS certyfikaty (G1 public cert) mogą być shared — ale session keys nigdy.

BAN-03: Lateral Traffic between Operators. Zakazane: jakiegokolwiek ruch sieciowy bezpośrednio między środowiskami operatorów (Operator A Zone 3 → Operator B Zone 3). Komunikacja między operatorami wyłącznie przez kontrolowane kanały (Matrix rooms, shared files via CDR).

BAN-04: Mutable Production Components. Zakazane: modyfikacja komponentów produkcyjnych in-place (SSH + apt upgrade, kubect exec + manual change, manual config edit). Wszystkie zmiany przez IaC/GitOps.

BAN-05: Plaintext Secrets in Code/Config. Zakazane: przechowywanie haseł, kluczy API, certyfikatów w plaintext w repozytorium Git, Terraform state (unencrypted), konfiguracji. Wszystkie secrets w Vault/SOPS, injected at runtime.

BAN-06: Direct Zone 0 → Zone 3 Access. Zakazane: terminal operatora nie może komunikować się bezpośrednio z workloadem — cały ruch przechodzi przez G1 → G2.

BAN-07: Zone 3 → Zone 5 Access. Zakazane: workloady operatorów nie mogą komunikować się z management plane. Zero ścieżek sieciowych z Zone 3 do Zone 5.

BAN-08: Single-Factor Authentication. Zakazane (dla STATE/SOVEREIGN): logowanie wyłącznie hasłem bez FIDO2. Silnie odradzane (dla STANDARD/PRO): single-factor powinien generować security warning.

BAN-09: WireGuard as Primary Transport. Zakazane: WireGuard nie może być używany jako główny transport VPN. Patrz 26.7.

BAN-10: Unattested Workloads in STATE Tier. Zakazane (dla STATE/SOVEREIGN): uruchomienie workloadu bez weryfikacji attestation (TEE measurement). Workload bez attestation nie otrzymuje sesji.

29.3 Zero Trust patterns — konkretne implementacje ZT w SYLION

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 25.3, 26.1, 27.4, 27.8, 29.1

Zero Trust w SYLION nie jest sloganem — jest zbiorem konkretnych wzorców implementacyjnych, z których każdy adresuje aspekt modelu „nigdy nie ufaj, zawsze weryfikuj”.

ZT-01: Identity Verification at Every Access. Każdy request do zasobu wymaga weryfikacji tożsamości. Implementacja: session token (JWT) weryfikowany przy każdym żądaniu sesji. Token zawiera: operator ID, tenant ID, tier, workload_set, device_id, posture_score. Token ma krótki lifetime (1h), refresh silent (5 min przed exp). Nie istnieje „zaufana sesja” trwająca bez rewalidacji — session broker re-evaluates co 5 minut.

ZT-02: Device Posture Continuous Assessment. Device posture nie jest jednorazowym sprawdzeniem przy loginie — jest ciągle monitorowana. Implementacja: G2 zbiera atrybuty urządzenia: OS version, patch level, encryption status, FIDO2 enrollment, VPN kill switch status, jailbreak/root detection. Score (0–100) wyliczany z weighted attributes. Re-evaluation: co 5 minut (configurable). Threshold: score < 70 → session warning + enhanced monitoring; score < 50 → session termination. Score < 30 → session termination + security alert + device quarantine recommendation.

ZT-03: Least Privilege Access. Operator dostaje dostęp wyłącznie do zasobów wymaganych przez jego rolę. Implementacja: RBAC (base permissions) + ABAC (context-dependent restrictions) + workload_set (operator widzi tylko swoje workloady). Tenant admin nie widzi infrastruktury. Operator nie widzi konfiguracji. Audytor ma read-only. Break-glass: eskalacja uprawnień wyłącznie z dwuosobową autoryzacją i pełnym audit trail.

ZT-04: Micro-perimeter per Operator. Zamiast jednego perimetru sieci, każdy operator ma własny mikroperymetr. Implementacja: network namespace per operator (Zone 3), eBPF policies (allow only: operator ↔ G2, operator → approved Zone 4 services), no lateral (operator ↔ operator blocked). Perymetr jest dynamiczny — rozszerzany/ograniczany na podstawie polityki (np. w godzinach pracy operator ma dostęp do env-crm, po godzinach — tylko env-matrix).

ZT-05: Encrypted Everything. Cały ruch jest szyfrowany — even internal, between trusted components. Implementacja: IPsec IKEv2 (terminal → G1), mTLS (G1 → G2, G2 → workload, workload → Zone 4 services), E2E encryption (Matrix communication, Olm/Megolm). Encryption at rest: LUKS2 (workload storage), AES-256 (log storage, backup), HSM-backed keys. No plaintext anywhere — even within Zone 3.

ZT-06: Assume Breach. Architektura zakłada, że każdy komponent może być skompromitowany — i definiuje, co atakujący zyskuje (minimalizacja). Implementacja: blast radius analysis per component (patrz 27.12), rebuild-first (nie diagnozuj — zniszcz i odbuduj), forensic-ready (snapshots, immutable logs), compartmentalization (kompromitacja G1 ≠ kompromitacja G2 ≠ kompromitacja workloadu).

29.4 Segmentation patterns — jak mikrosegmentacja jest realizowana technicznie (eBPF, IPsec, OPA)

Status: [N] Normatywny Odbiorca: Architekt | Infra | Dev Wpływ na baseline: Krytyczny Powiązane rozdziały: 25.2, 26.3, 27.5, 29.3

Mikrosegmentacja w SYLION jest wielowarstwowa — realizowana na poziomie sieci (L3/L4), aplikacji (L7) i polityki.

SEG-01: Network Namespace Isolation (L3). Każdy operator w Zone 3 ma dedykowany Linux network namespace. Namespace zawiera: veth pair (połączenie z hostem), IP address (z per-operator subnet, np. 10.3.OperatorID.0/24), routing table (default route → G2), iptables/nftables rules (default DROP, allow only: → G2, → approved Zone 4 services). Namespace jest tworzony przez Firecracker orchestrator przy provisioning operatora i niszczone przy offboarding. Bezpieczeństwo: kernel network namespace zapewnia, że procesy w jednym namespace nie widzą ruchu w innym (nawet jeśli działają na tym samym hoście).

SEG-02: eBPF Policy Enforcement (L3/L4/L7). eBPF programs (Cilium lub custom) na hoście Zone 3 egzekwują polityki ruchu: (1) Per-operator egress policy: env-browser → egress proxy IP:443 (ALLOW), env-matrix → Matrix homeserver IP:8448 (ALLOW), env-signal → Signal egress proxy IP:443 (ALLOW), all other → DROP. (2) Anti-lateral policy: source namespace A → destination namespace B → DROP (bezwzględnie). (3) Rate limiting: per-operator bandwidth limits (DDoS prevention

from compromised workload). eBPF jest preferowany nad iptables/nftables, ponieważ: wyższa wydajność (in-kernel, no context switch), lepsze observability (metrics, tracing), programmability (L7 inspection without full proxy).

SEG-03: IPsec within Zone (opcjonalnie, STATE/SOVEREIGN). Dla najwyższego tieru: ruch wewnątrz Zone 3 (G2 → workload) również szyfrowany IPsec (transport mode) lub mTLS. Zapewnia ochronę nawet w przypadku kompromitacji hypervisora hosta (atakujący widzi tylko ciphertext). Narzut wydajnościowy: <5% (AES-NI acceleration). Konfiguracja: strongSwan w transport mode (per-operator SA).

SEG-04: OPA Policy Segmentation (L7). Policy Engine (OPA) egzekwuje segmentację na poziomie aplikacyjnym: (1) Workload access policy: operator z rolą OPERATOR może uruchomić env-matrix, env-browser; nie może uruchomić env-crm (jeśli nie ma roli CRM_USER). (2) Data classification policy: operator z clearance INTERNAL nie może otworzyć dokumentu CONFIDENTIAL (enforcement w env-office). (3) Time-based policy: po godzinach pracy operator ma dostęp wyłącznie do env-matrix (nie env-crm, nie env-office).

SEG-05: Zone Boundary Enforcement. Granice stref (Zone 0–5) egzekwowane na poziomie infrastruktury: firewall rules na dedicated firewall nodes (lub eBPF on host), routing tables (Zone 3 nie ma route do Zone 5 subnet), VLAN/VRF (fizyczna lub logiczna separacja). Zone boundary enforcement jest niezależne od per-operator segmentation — działa na innym poziomie (zone-level, nie operator-level).

29.5 Session isolation patterns — per-session state, token lifecycle, cleanup

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 27.4, 27.5, 29.3, 30.2, 31.1, 31.2

Izolacja sesji zapewnia, że stan jednej sesji (operatora A) nie wpływa na inną sesję (operatora B), a zakończenie sesji skutkuje pełnym usunięciem stanu efemerycznego.

SES-01: Per-Session Token. Każda sesja ma unikalny JWT token (patrz 27.4). Token jest bound to: session ID (unique), operator ID, device ID, originating IP. Token nie może być przeniesiony na inną sesję, inne urządzenie, inny IP (token binding). Próba użycia tokenu z innego urządzenia/IP → immediate revocation + security alert.

SES-02: Per-Session Workload State. Domyślnie workloady są efemeryczne: stan sesji (otwarte dokumenty, cache przeglądarki, clipboard) istnieje wyłącznie w RAM microVM. Zamknięcie sesji → zniszczenie microVM → stan utracony. Wyjątek: persistent storage (env-office documents, env-crm database) — przeżywa sesję, ale jest encrypted per operator i niedostępny dla innych sesji.

SES-03: Cleanup Protocol. Po zakończeniu sesji (logout, timeout, revocation): (1) Session broker: unieważnia token (dodaje do revocation list, propagacja <5s). (2) Session broker → orchestrator: stop workloads. (3) Orchestrator: sends ACPI shutdown → wait 10s → force kill → destroy microVM. (4) Network: destroy network namespace per operator (jeśli session = last session for this operator). (5) Ephemeral storage: cryptographic erase (overwrite encryption key of overlay, <1s). (6) Audit: session end event logged (session ID, duration, reason, cleanup status).

SES-04: Concurrent Session Control. Policy: max concurrent sessions per operator. Default: 1 (STATE/SOVEREIGN), 2 (PRO), 3 (STANDARD). Nowa sesja powyżej limitu: deny (strict mode) lub terminate oldest (graceful mode, configurable). Cel: zapobiec session hijacking (atakujący otwiera sesję z innego urządzenia) i resource abuse.

SES-05: Session Recording (opcjonalnie, STATE/SOVEREIGN). Nagrywanie sesji: pixel stream zapisywany do encrypted storage (Zone 4). Retention: configurable (30 dni default). Access: AUDITOR + dual authorization. Cel: forensic, compliance (regulacyjne wymogi w sektorze finansowym/rządowym). Privacy: operator informowany o nagrywaniu (banner), explicit consent required (w zależności od jurysdykcji). Format: lossless compression (zstd), encrypted per session (AES-256-GCM, key derived from HSM).

29.6 Runtime security patterns — immutable images, read-only rootfs, seccomp, AppArmor

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 26.9, 27.5, 29.3, 29.7

Runtime security patterns definiują, jak workloady i usługi SYLION są chronione w czasie wykonywania — po uruchomieniu, ale przed zakończeniem.

RUN-01: Read-Only Root Filesystem. Każda microVM i kontener ma read-only rootfs (mount z flagą ro). Writeable: wyłącznie /tmp (tmpfs, ephemeral, cleared on restart), /home (overlay, per-operator, encrypted), /var/log (ephemeral, forwarded to log pipeline). Cel: zapobiec modyfikacji binaries, configuration, libraries przez atakującego (nawet z root access w workload). Implementacja: Firecracker rootfs jako squashfs (read-only by design), overlay mount for writable layers.

RUN-02: Seccomp Profiles. Każdy workload type ma dedicated seccomp profile (BPF filter) ograniczający dozwolone syscalls. Profile: env-matrix (allow: networking, file I/O, crypto — deny: mount, ptrace, reboot, kexec), env-browser (allow: networking, file I/O, GPU/rendering — deny: mount, ptrace, raw sockets), env-signal (similar to env-matrix, plus Signal-specific), env-office (allow: file I/O, rendering — deny: networking direct, mount), env-crm (allow: networking, file I/O, database ops — deny: raw sockets). Seccomp w trybie „deny by default, allow listed” — niezadeklarowany syscall → EPERM + audit event.

RUN-03: AppArmor / SELinux Profiles. Mandatory Access Control (MAC) profiles per workload type. AppArmor (preferowany na Alpine/Debian-based) lub SELinux (na Fedora/RHEL-based). Profile ograniczają: file access (whitelist katalogów, deny access to /etc/shadow, /proc/kcore), network access (enforce per-workload egress policy na poziomie MAC), capability restrictions (no CAP_SYS_ADMIN, no CAP_NET_RAW). Profile testowane w CI/CD (AppArmor parser validation), deployed via IaC.

RUN-04: No Root in Workload. Procesy w workloadach działają jako non-root user (uid > 1000). Rootless containers/microVMs: brak capability escalation, brak suid binaries (nosuid mount flag). Wyjątek: init process (PID 1) działa jako root w microVM — ale minimalizowany (systemd-less, custom init script lub s6/dinit).

RUN-05: Resource Limits. Per-workload resource limits: CPU (cgroups v2 cpu.max), RAM (memory.max, OOM killed if exceeded), storage (disk quota per overlay), network (eBPF rate limiter). Cel: zapobiec resource starvation (jeden workload nie może zużyć zasobów hosta) i side-channel attacks (resource-based timing attacks).

RUN-06: Runtime Integrity Monitoring. Opcjonalnie: runtime file integrity monitoring (AIDE/osquery/Falco) w workloadach. Monitoring: changes to critical files (binaries, configs, libraries), unexpected process execution, unexpected network connections. Alert → SIEM → SOC triage.

29.7 Immutable infra patterns — GitOps, image pinning, no drift tolerance

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 26.9, 27.7, 29.1, 29.6

Wzorce immutable infrastructure definiują, jak zasada „nie modyfikuj, zastąp” jest realizowana w praktyce operacyjnej.

IMM-01: GitOps — Single Source of Truth. Cały desired state systemu jest zdefiniowany w repozytoriach Git (Zone 5). Repozytoria: (1) infra-core: Terraform modules (infrastructure), (2) infra-config: Ansible roles (OS configuration), (3) policy-repo: OPA policies (access control), (4) images-repo: Dockerfiles/Firecracker image definitions, (5) app-config: application configuration (Keycloak realm export, monitoring dashboards). GitOps controller (Flux/ArgoCD) reconciles Git state → cluster state. Drift: jakiegokolwiek odchylenie cluster state od Git state → automatic reconciliation (rollback to Git state) + alert.

IMM-02: Image Pinning by Digest. Wszystkie images (container, microVM) referenced by digest (sha256:abc...), nie by tag (latest, v1.2.3). Cel: tag może zostać nadpisany (supply chain attack); digest jest immutable. Implementacja: CI/CD pipeline generuje image → pushes to registry → records digest in Git → GitOps deploys by digest. Update: new image → new digest → PR in Git → review → merge → deploy.

IMM-03: No SSH / No Interactive Access. SSH na hostach produkcyjnych jest domyślnie wyłączony (port closed, sshd not installed). Interactive access: wyłącznie przez break-glass procedure: (1) operator zgłasza potrzebę, (2) PLATFORM_ADMIN autoryzuje (dual approval), (3) Vault issues short-lived SSH certificate (1h lifetime), (4) bastion session recorded, (5) po zakończeniu: SSH certificate expires, host rebuild scheduled (tainted — interactive access = no longer immutable). Codzienne operacje: IaC only.

IMM-04: Blue/Green Infrastructure Updates. Aktualizacja infrastruktury: (1) build new (terraform apply new resources alongside old), (2) verify new (automated tests, smoke tests), (3) switch traffic (DNS/LB update from old → new), (4) observe (30 min soak period), (5) destroy old (terraform destroy old resources). Rollback: switch traffic back to old (if old not yet destroyed). Czas: <30 min per component update, <2h per full infrastructure update.

IMM-05: Drift Detection and Response. Continuous drift detection: (1) Terraform: terraform plan (dry-run) every 1h — if changes detected (drift) → alert + auto-remediation (terraform apply to restore desired state). (2) Container/microVM: image digest comparison (running vs desired) every 15 min — if mismatch → alert + auto-rollback. (3) Configuration: Ansible —check every 4h — if drift → alert + auto-apply. Drift is treated as security incident (potential tampering) — event logged, SOC notified.

29.8 Recovery patterns — rebuild-first, blue/green for infra, sealed secrets restore

Status: [N] Normatywny Odbiorca: Architekt | Infra | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.4, 26.9, 27.12, 28.9, 29.7

Recovery patterns definiują, jak system jest odtwarzany po awarii, incydencie bezpieczeństwa lub katastrofie.

REC-01: Rebuild-First (Don't Diagnose, Rebuild). W przypadku podejrzenia kompromitacji: nie diagnozuj na żywym systemie (ryzyko: atakujący obserwuje forensic, niszczy ślady). Procedura: (1) isolate (network quarantine — eBPF rule: DROP all), (2) snapshot (forensic copy of disk, memory dump if possible), (3) destroy (terraform destroy compromised resources), (4) rebuild (terraform apply from known-good state), (5) verify (automated tests), (6) restore traffic. (7) Forensic analysis: offline, na snapshot, przez dedykowany zespół. Czas rebuildu: <30 minut per operator environment, <4 godziny per full platform.

REC-02: Blue/Green for Infrastructure Recovery. Po katastrofie (data center loss): aktywacja secondary region (blue/green switchover — patrz 28.9). Primary staje się „blue” (destroyed/unavailable), secondary staje się „green” (active). Po przywróceniu primary: primary staje się nowym standby (odwrócenie ról). Nie ma „powrotu do primary” — po failover secondary jest nowym primary.

REC-03: Sealed Secrets Restore. Secrets (Vault state) chronione przez: (1) Vault auto-unseal with HSM (Vault restarts → auto-unseals using HSM-stored key), (2) Vault HA (standby node takes over), (3) Vault backup (encrypted Vault snapshots in backup storage). Restore procedure: (1) Deploy fresh Vault from IaC, (2) restore from encrypted snapshot, (3) auto-unseal with HSM, (4) verify (secret access test), (5) re-issue short-lived certificates (old ones may have expired during outage).

REC-04: HSM Recovery. HSM failure scenarios: (1) HSM temporary unavailable: Vault cache allows continued operation for short period (token validation uses cached certs), new cert issuance blocked until HSM restored. (2) HSM permanent failure: restore from HSM backup (ceremony — requires quorum of M-of-N key custodians, physical presence). DR HSM in secondary location: initialized from backup during DR activation. (3) HSM compromise: worst case — full PKI re-key. Procedure: generate new root CA on new HSM, issue new intermediate CAs, re-issue all end-entity certificates, revoke old CA. Time: 4–24h depending on scale.

REC-05: Operator Environment Recovery. Operator environment lost (microVM crash, host failure): (1) Session broker detects disconnect (heartbeat miss, 30s), (2) orchestrator provisions new microVM on healthy host (<150ms boot), (3) persistent storage re-attached (encrypted volume, if applicable), (4) operator re-connects (automatic reconnect from terminal, <5s visible interruption). Ephemeral state (clipboard, browser cache, temp files): lost. Persistent state (documents, CRM data): preserved.

29.9 API and event patterns — async events for provisioning, sync for policy decisions

Status: [R] Rekomendowany Odbiorca: Architekt | Dev Wpływ na baseline: Średni Powiązane rozdziały: 27.4, 27.6, 27.10, 31.4, 31.8, 31.9

Wzorce API i zdarzeń definiują, jak komponenty SYLION komunikują się między sobą — synchronicznie (request/response) lub asynchronicznie (event/queue).

API-01: Synchronous for Policy Decisions. Ewaluacja polityk (G2/Policy Engine) jest synchroniczna: request → evaluate → response (allow/deny). Uzasadnienie: decyzja o dostępie nie może być odroczone — operator czeka na wynik. Latency budget: <10ms (OPA evaluation), <50ms (end-to-end including network). Retry: nie (fail-closed — jeśli Policy Engine niedostępny, access denied, nie retry). Fallback: local policy cache w G2 (stale policies used if Policy Engine unreachable, with alert — max staleness: 15 min).

API-02: Asynchronous for Provisioning. Provisioning operatora jest asynchroniczny: request (Admin Portal → Management API) → queue (task in provisioning pipeline) → execute (IaC steps) → callback/webhook (provisioning complete/failed). Uzasadnienie: provisioning jest długotrwały (minutes), multi-step, may require manual approval. Implementacja: task queue (Redis/RabbitMQ), saga orchestrator, webhook notification on completion.

API-03: Event-Driven for Telemetry. Logi i metryki: event-driven (fire-and-forget from source, reliable delivery by pipeline). Flow: source (workload, gateway, service) → agent (Fluent Bit, push mode) → aggregator (Fluentd/Vector, Zone 4) → SIEM ingest / metrics store. At-least-once delivery (agent buffers on disk, retries on failure). Ordering: per-source FIFO (sufficient for log analysis). Backpressure: agent buffers to disk (up to 1GB), aggregator rate-limits on ingest.

API-04: Webhook for External Integration. SYLION → klient: webhook notifications (asynchronous, push model). Events: provisioning complete, offboarding complete, security incident, certificate expiring. Reliability: retry (3x, exponential backoff), dead letter queue (after 3 failures → stored, alert to admin). Idempotency: each webhook includes unique event_id — client should deduplicate by event_id.

API-05: REST for Management. Management API: RESTful, versioned (/v1/), JSON payloads. CRUD operations for: operators, policies, integrations, reports. Authentication: OAuth 2.0 + mTLS. Rate limiting: per tenant, per API key. Pagination: cursor-based (for large result sets). Error responses: structured (error_code,

message, details, request_id). Deprecation policy: old API versions supported for minimum 12 months after deprecation announcement.

29.10 Antywzorze projektowe i operacyjne — lista antywzorców z konkretnymi przykładami

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 29.1, 29.2

Antywzorze to powtarzające się błędy architektoniczne i operacyjne, które podważają bezpieczeństwo, niezawodność lub audytowalność systemu. Poniższa lista stanowi „katalog zakazów” z konkretnymi przykładami z kontekstu SYLION.

ANTI-01: God Gateway. Antywzorzec: jeden monolityczny gateway, który terminuje transport, ewaluuje polityki, routuje sesje, przetwarza CDR, zarządza tożsamością — wszystko w jednym procesie. Dlaczego zły: single point of compromise (kompromitacja = pełen dostęp), impossible to scale independently, impossible to certify independently. SYLION: unikamy — split G1/G2, CDR w Zone 4, IAM w Zone 5.

ANTI-02: Trust-On-First-Use (TOFU) without Verification. Antywzorzec: system ufa urządzeniu po pierwszym połączeniu, bez ciągłej weryfikacji. Dlaczego zły: device compromise after initial trust → full access. SYLION: unikamy — continuous device posture assessment (29.3 ZT-02).

ANTI-03: Pet Servers. Antywzorzec: serwery produkcyjne traktowane jak „zwierzęta domowe” — ręcznie konfigurowane, patchowane, z unikalnymi nazwami, nieodtworzalne. Dlaczego zły: drift, inconsistency, impossible to audit, impossible to rebuild. SYLION: unikamy — cattle not pets (immutable infrastructure, IaC, rebuild-first).

ANTI-04: Security by Obscurity. Antywzorzec: bezpieczeństwo oparte na ukryciu (secret protocol, custom encryption, undocumented API). Dlaczego zły: fails when secret is revealed (and it always is). SYLION: unikamy — open protocols (Matrix, IPsec, OIDC), standard crypto (AES-256, ECDH, ML-KEM), documented architecture (ta Księga).

ANTI-05: Blast Radius Neglect. Antywzorzec: brak analizy, co się dzieje po kompromitacji komponentu X. Dlaczego zły: kompromitacja jednego komponentu eskaluje do pełnej kompromitacji. SYLION: unikamy — explicit blast radius analysis per component (27.12), compartmentalization (zones, micro-segmentation).

ANTI-06: Log-and-Forget. Antywzorzec: logi zbierane, ale nigdy nie analizowane, nie alertowane, nie przeglądane. Dlaczego zły: logi bez analizy to false sense of security. SYLION: unikamy — SIEM z active rules, SOC monitoring, automated alerting, periodic log review.

ANTI-07: Orphaned Credentials. Antywzorzec: credential (API key, certificate, SSH key) stworzony dla projektu/osoby, nigdy nie wygasający, zapomniany. Dlaczego zły: stale credential = permanent backdoor. SYLION: unikamy — short-lived certificates (24h workload, 30d operator), automated rotation, Vault dynamic secrets, regular credential audit.

ANTI-08: Configuration Snowflake. Antywzorzec: każdy serwer ma unikalną konfigurację powstałą z nakładania poprawek. Dlaczego zły: impossible to reproduce, impossible to audit. SYLION: unikamy — IaC (Terraform/Ansible), GitOps, drift detection.

ANTI-09: Single Region Single Vendor. Antywzorzec: cała infrastruktura w jednym regionie jednego dostawcy. Dlaczego zły: vendor outage = total outage. SYLION: unikamy — multi-cloud support (IaC vendor-agnostic), DR/secondary region, sovereign on-premise option.

ANTI-10: Excessive Shared State. Antywzorzec: wiele komponentów współdzieli jedną bazę danych / one big shared store. Dlaczego zły: failure in shared store = cascade failure; data isolation broken. SYLION: unikamy — per-service database, per-operator storage, Zone separation.

Rozdział 30. Model danych wysokiego poziomu

30.1 Główne byty systemowe — pełna lista encji

Status: [N] Normatywny Odbiorca: Architekt | Dev | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 17.2, 24.2, 27.1–27.12, 30.2–30.10

Model danych SYLION obejmuje wszystkie encje, których system śledzi, przetwarza i przechowuje. Encje są pogrupowane w domeny logiczne, z których każda jest opisana w kolejnych podrozdziałach.

Domena: Tożsamość i dostęp. Operator — osoba korzystająca z platformy. Tenant — organizacja (klient) grupująca operatorów. Role — rola RBAC przypisana do operatora (OPERATOR, TENANT_ADMIN, PLATFORM_ADMIN, AUDITOR, SOC_ANALYST). Attribute — atrybut ABAC operatora (device_posture_score, risk_score, classification_clearance). Policy — polityka OPA definiująca reguły dostępu. PolicyDecision — wynik ewaluacji polityki (allow/deny + reasons + timestamp). Credential — materiał uwierzytelniający (FIDO2 key, OIDC token, client certificate). IdentityProvider — zewnętrzny IdP sfederowany z SYLION (Azure AD, Okta).

Domena: Sesja i workload. Session — aktywna sesja operatora (token, workload_set, device_id, start_time). Environment — środowisko workloadu (env-matrix, env-browser, env-office, env-signal, env-crm, env-voice). MicroVM — instancja Firecracker (image_digest, resource_allocation, network_namespace, status). WorkloadImage — obraz microVM w registry (digest, type, version, signed_by, scan_results).

Domena: Komunikacja. MatrixRoom — pokój Matrix (room_id, tenant_id, members, power_levels). MatrixMessage — wiadomość (event_id, room_id, sender, encrypted_content, timestamp). VoiceSession — sesja głosowa (call_id, participants, codec, start/end_time).

Domena: Transfer i CDR. File — plik w systemie (file_id, name, format, size, classification_label). FileTransfer — transfer pliku (transfer_id, source_workload, destination_workload, direction, timestamp). CDRResult — wynik przetwarzania CDR (original_hash, reconstructed_hash, findings, decision). Quarantine — kwarantanna pliku (file_id, reason, quarantine_timestamp, review_status).

Domena: Infrastruktura i aktywa. Device — terminal operatora (device_id, type, os_version, posture_score, last_check). Router — opcjonalny router VPN (router_id, model, config_version, last_seen). Host — serwer fizyczny/VM (host_id, zone, role, os_version, compliance_status). HSM — moduł bezpieczeństwa (hsm_id, type, firmware_version, key_count, last_ceremony_date).

Domena: Kryptografia. Certificate — certyfikat X.509 (serial, subject, issuer, validity, key_type, status). Key — klucz kryptograficzny (key_id, type, algorithm, hsm_slot, created_at, last_used). Secret — sekret w Vault (path, version, created_at, last_rotated, lease_ttl). RotationEvent — zdarzenie rotacji klucza/sekretu (event_id, target, old_version, new_version, triggered_by).

Domena: Logi i zdarzenia. LogEvent — rekord logu (event_id, timestamp, source, category, severity, payload). Alert — alert bezpieczeństwa (alert_id, rule_id, severity, source_events, status, assigned_to). Incident — incydent bezpieczeństwa (incident_id, severity, description, status, timeline, remediation). AuditRecord — rekord audytowy (record_id, actor, action, target, result, timestamp).

Domena: Integracja. Connector — integracja zewnętrzna (connector_id, type, endpoint, auth_method, status). DataContract — kontrakt danych integracji (contract_id, connector_id, schema_version, sla).

30.2 Operator, tenant, environment, session — relacje i cykl życia

Status: [N] Normatywny Odbiorca: Architekt | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 17.2, 24.2, 27.4, 27.5, 29.5, 30.1

Relacje między głównymi encjami operacyjnymi tworzą hierarchię: Tenant → Operator → Session → Environment/MicroVM.

Tenant. Tenant jest najwyższym poziomem izolacji organizacyjnej. Każda organizacja klienta = jeden tenant. Atrybuty: tenant_id (UUID), name, tier (STANDARD/PRO/STATE), created_at, status (ACTIVE/SUSPENDED/ARCHIVED), max_operators, config (polityki domyślne, integracje). Lifecycle: (1) Created: provisioning (IaC + Keycloak realm). (2) Active: operatorzy mogą logować się. (3) Suspended: logowanie zablokowane, dane zachowane (np. brak płatności). (4) Archived: dane przechowywane (per retention policy), infrastruktura zniszczona. (5) Destroyed: dane usunięte (cryptographic erase), tenant ID zachowany w audit log.

Operator. Operator należy do dokładnie jednego tenanta. Atrybuty: operator_id (UUID), tenant_id, display_name (lub pseudonim), email (opcjonalnie), roles (lista), credentials (FIDO2 keys, IdP links), workload_set (dozwolone workloady), status (ACTIVE/SUSPENDED/OFFBOARDED), created_at, last_login. Lifecycle: (1) Provisioned: tożsamość w Keycloak, role przypisane, FIDO2 enrolled, terminal skonfigurowany. (2) Active: operator loguje się, tworzy sesję. (3) Suspended: logowanie zablokowane, dane zachowane. (4) Offboarded: tożsamość odwołana, FIDO2 revoked, certyfikaty revoked, workload persistent storage destroyed, operator ID zachowany w audit log.

Session. Sesja jest tymczasową relacją między operatorem a zestawem workloadów. Atrybuty: session_id (UUID), operator_id, device_id, token (JWT), workload_set (active workloads), start_time, last_heartbeat, status (ACTIVE/IDLE/TERMINATED), termination_reason. Relacja: Operator 1:N Session (ale z concurrent limit per policy). Session 1:N MicroVM (jedna sesja uruchamia wiele workloadów). Lifecycle: (1) Created: operator authenticated, policy evaluated, token issued. (2) Active: heartbeat OK, workloads running. (3) Idle: no operator input for idle_timeout period → warning. (4) Terminated: logout / timeout / admin revoke / policy violation → cleanup.

Environment / MicroVM. Instancja workloadu w sesji operatora. Atrybuty: vm_id (UUID), session_id, operator_id, workload_type (env-matrix/browser/etc.), image_digest, host_id, network_namespace, ip_address, status (STARTING/RUNNING/STOPPING/DESTROYED), resource_allocation (cpu, ram). Relacja: Session 1:N MicroVM. Lifecycle: (1) Starting: orchestrator creates VM, boot <150ms. (2) Running: operator interacts. (3) Stopping: session end, ACPI shutdown. (4) Destroyed: VM killed, ephemeral storage erased.

30.3 Tożsamość, polityka, atrybut, decyzja — model decyzyjny

Status: [N] Normatywny Odbiorca: Architekt | Dev | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 27.8, 27.9, 29.3, 31.4

Model decyzyjny definiuje, jak system podejmuje decyzje o dostępie na podstawie tożsamości, polityk i atrybutów kontekstowych.

Tożsamość (Identity). Tożsamość operatora jest kompozycją: (1) principal: operator_id + tenant_id, (2) authentication_evidence: FIDO2 assertion / OIDC token / SAML assertion, (3) device_binding: device_id + client_certificate. Tożsamość jest weryfikowana przy każdym loginie (strong verification: FIDO2 + device cert) i ciągle re-validowana (session token refresh + device posture re-evaluation).

Polityka (Policy). Polityka jest regułą zdefiniowaną w OPA/Rego, która mapuje (identity, resource, context) → decision. Polityki są wielopoziomowe: (1) Platform policies: definiowane przez SYLION, obowiązkowe (np. „Zone 3 → Zone 5 always denied”). (2) Tier policies: definiowane per tier (np. „STATE/SOVEREIGN: FIDO2 mandatory”). (3) Tenant policies: definiowane przez TENANT_ADMIN (np. „po godzinach 18:00 access only env-matrix”). (4) Workload policies: definiowane per workload type (np. „env-browser: clipboard disabled”). Precedence: platform > tier > tenant > workload. Conflict resolution: deny overrides allow.

Atrybut (Attribute). Atrybuty wchodzące do ewaluacji polityki: (1) Statyczne: operator_role, tenant_tier, classification_clearance. (2) Dynamiczne: device_posture_score (0–100, re-evaluated co 5 min), time_of_day, source_network_type (corporate/public/mobile), risk_score (0–100, from SIEM/AI). (3) Kontekstowe: requested_resource (workload type), requested_action (start session / transfer file / access API). Atrybuty dynamiczne są pobierane w real-time przy każdej ewaluacji — nie cachowane (z wyjątkiem device_posture, cachowane na 5 min).

Decyzja (PolicyDecision). Wynik ewaluacji: (1) ALLOW: dostęp przyznany, z opcjonalnymi obligations (np. „enable session recording”, „reduce clipboard to text-only”). (2) DENY: dostęp odmówiony, z reasons (np. „device posture score below threshold”, „operator not in allowed role”). (3) ABSTAIN: polityka nie ma opinii (pass to next policy in chain). Decyzja jest logowana jako AuditRecord: input (identity, resource, context), output (decision, reasons, obligations), metadata (policy_version, evaluation_time_ms, timestamp). Latency budget: <10ms per evaluation (OPA), <50ms end-to-end (including attribute fetch).

Decision caching. Decyzje nie są cachowane (każdy request = fresh evaluation). Wyjątek: session token contains cached policy result (workload_set) — ale token jest re-issued co 1h (i re-evaluated co 5 min by session broker). Caching policy bundles (OPA data/bundle): yes, updated every 30s from policy repo.

30.4 Plik, transfer, kwarantanna, eksport — pipeline danych

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 26.10, 27.6, 30.1, 31.3

Pipeline danych plikowych w SYLION obejmuje cały cykl życia pliku: od momentu wejścia do systemu, przez CDR, po dostarczenie lub kwarantannę.

Encja: File. Atrybuty: file_id (UUID, assigned at ingestion), original_name, declared_mime_type, detected_mime_type (libmagic), size_bytes, classification_label (UNRESTRICTED/INTERNAL/CONFIDENTIAL/SECRET/TOP_SECRET — STATE only), hash_original (SHA-256 pre-CDR), hash_reconstructed (SHA-256 post-CDR), status (STAGING/PROCESSING/DELIVERED/QUARANTINED/EXPORTED/DESTROYED), created_at, processed_at, delivered_at.

Encja: FileTransfer. Atrybuty: transfer_id (UUID), file_id, direction (INBOUND/OUTBOUND/INTERNAL), source (external URL / operator upload / workload → workload), destination (workload_id / operator_id / external endpoint), initiated_by (operator_id), approved_by (auto / admin_id — for sensitive exports), status (PENDING/CDR_PROCESSING/DELIVERED/REJECTED/EXPORTED), timestamps (initiated_at, processed_at, completed_at).

Encja: CDRResult. Atrybuty: cdr_id (UUID), file_id, transfer_id, engine_version, processing_time_ms, findings (list: removed macros, stripped metadata, sanitized images, etc.), decision (CLEAN/QUARANTINED/REJECTED), original_hash, reconstructed_hash, microvm_id (CDR microVM used). CDRResult jest immutable — raz wygenerowany, nigdy nie modyfikowany.

Encja: Quarantine. Atrybuty: quarantine_id (UUID), file_id, cdr_id, reason (unsupported format / suspicious content / CDR processing error / DLP match), quarantine_storage_path (encrypted), quarantined_at, review_status (PENDING_REVIEW/REVIEWED_RELEASE/REVIEWED_DESTROY), reviewed_by (admin_id), reviewed_at. Quarantine retention: 30 days (default), po czym automatic destroy (cryptographic erase).

Encja: Export. Atrybuty: export_id (UUID), file_id, transfer_id, destination (external endpoint / download), dlp_result (CLEAN/FLAGGED/BLOCKED), export_classification, approved_by, exported_at. Export DLP flow: plik z Zone 3 → DLP engine (Zone 4) → classification check → if FLAGGED: requires admin approval; if BLOCKED: denied; if CLEAN: exported with audit trail.

Lifecycle pliku — inbound. (1) Upload: operator uploads file from terminal → file received by G2/CDR trigger. (2) Staging: file written to CDR staging (Zone 4, encrypted). (3) CDR: file sent to CDR microVM → parse → disarm → reconstruct → validate. (4) Decision: CLEAN → deliver to workload; QUARANTINE → move to quarantine storage + alert operator; REJECT → destroy + alert. (5) Delivery: reconstructed file placed in operator workload (Zone 3). (6) Audit: full trail (file hashes, CDR result, timestamps) written to log store.

Lifecycle pliku — outbound. (1) Request: operator requests export from workload. (2) DLP: file sent to DLP engine → content classification → policy check. (3) Decision: CLEAN → export allowed; FLAGGED → pending admin approval; BLOCKED → denied + alert. (4) Export: file delivered to destination (download, external API, email). (5) Audit: full trail.

30.5 Log, zdarzenie, alert, incydent — model zdarzeń

Status: [N] Normatywny Odbiorca: Architekt | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.4, 27.6, 27.7, 30.1, 31.5, 31.6

Model zdarzeń definiuje hierarchię: LogEvent → Alert → Incident, z przejrzystym przepływem od surowego zdarzenia do reakcji.

Encja: LogEvent. Atrybuty: event_id (UUID v7 — time-ordered), timestamp (nanosecond precision, UTC), source (component_id: G1, G2, orchestrator, CDR, Keycloak, etc.), category (SESSION/POLICY/CDR/ADMIN/INFRA/AUTH/NETWORK), severity (DEBUG/INFO/WARN/ERROR/CRITICAL), actor (operator_id / admin_id / system), action (login/logout/policy_eval/file_transfer/config_change/etc.), target (resource affected), result (SUCCESS/FAILURE/DENIED), details (structured JSON payload with action-specific fields), hash_previous (hash of previous event from same source — chain integrity). Retention: per tier (12 months / 3 years / 7 years). Immutability: append-only store, hash chain, periodic integrity verification.

Encja: Alert. Alert jest generowany automatycznie przez reguły SIEM na podstawie jednego lub wielu LogEvents. Atrybuty: alert_id (UUID), rule_id (which SIEM rule triggered), severity (LOW/MEDIUM/HIGH/CRITICAL), source_events (list of event_ids that triggered), description (human-readable), status (NEW/ACKNOWLEDGED/IN_PROGRESS/RESOLVED/FALSE_POSITIVE), assigned_to (SOC analyst), created_at, updated_at, resolved_at, resolution_notes. Przykładowe reguły: „5 failed logins from same device in 5 min” → MEDIUM alert, „policy violation: Zone 3 → Zone 5 traffic detected” → CRITICAL alert, „CDR quarantine: 3+ files from same operator in 1h” → HIGH alert.

Encja: Incident. Incydent jest tworzony manualnie (SOC analyst) lub automatycznie (eskalacja z alertu CRITICAL). Atrybuty: incident_id (UUID), severity (P1/P2/P3/P4 — per severity matrix), description, status (OPEN/INVESTIGATING/CONTAINMENT/ERADICATION/RECOVERY/CLOSED/POST_MORTEM), timeline (chronological list of events, actions, decisions), related_alerts (list of alert_ids), affected_operators (list), affected_components (list), remediation_actions (list: isolate, rebuild, revoke, etc.), post_mortem_url (link to post-mortem document), created_at, closed_at. SLA: P1 → response <15 min, containment <1h; P2 → response <1h, containment <4h; P3 → response <4h; P4 → next business day.

Encja: AuditRecord. Rekord audytowy jest specjalnym typem LogEvent z gwarancją immutability i completeness. Każda operacja zmieniająca stan systemu generuje AuditRecord: provisioning, offboarding, policy change, config change, certificate issuance/revocation, HSM operation, admin action. AuditRecord zawiera: who (actor), what (action + target), when (timestamp), where (source component), why (ticket/approval reference), result. AuditRecord nigdy nie jest modyfikowany ani usuwany — nawet przez PLATFORM_ADMIN.

30.6 Klucz, certyfikat, sekret, rotacja — model kryptograficzny

Status: [N] Normatywny Odbiorca: Architekt | Infra | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 24.4, 26.7, 26.8, 27.8, 30.1

Model kryptograficzny obejmuje wszystkie obiekty kryptograficzne w systemie, ich hierarchię, lifecycle i reguły rotacji.

Encja: Key. Atrybuty: key_id (UUID), type (ROOT_CA / INTERMEDIATE_CA / WORKLOAD / SESSION / ENCRYPTION / SIGNING), algorithm (ECDSA-P384, RSA-4096, AES-256, ML-KEM-768, ML-DSA-65), storage (HSM_SLOT / VAULT / EPHEMERAL_RAM), hsm_slot_id (if HSM), created_at, expires_at (if applicable), last_used_at, usage_count, status (ACTIVE/ROTATED/REVOKED/DESTROYED). Hierarchia: Root CA Key (HSM, never exported, 20-year validity) → Intermediate CA Key (HSM, per tenant, 5-year validity) → End-Entity Key (Vault/ephemeral, per operator/workload, hours-to-days validity).

Encja: Certificate. Atrybuty: serial_number, subject (CN, O, OU), issuer (CA), validity (not_before, not_after), key_type (algorithm + key_id reference), extensions (SAN, key usage, extended key usage), status (ACTIVE/EXPIRED/REVOKED), revocation_reason (if revoked), crl_entry, omsp_status. Typy certyfikatów: (1) Client IPsec cert (operator terminal, 30-day validity, auto-renewed). (2) Workload mTLS cert (per workload, 24h validity, auto-renewed). (3) Service mTLS cert (G1, G2, Zone 4 services, 30-day validity). (4) Public TLS cert (G1 public endpoint, Let's Encrypt/DigiCert, 90-day validity). (5) Code signing cert (CI/CD image signing, 1-year validity).

Encja: Secret. Atrybuty: path (Vault path: secret/tenant/X/database_password), version (Vault versioned KV), created_at, last_rotated_at, rotation_schedule (cron expression), lease_ttl (for dynamic secrets), accessor (who has access). Typy: (1) Static secret: API key, database password — rotated per schedule. (2) Dynamic secret: Vault-generated, short-lived, per-request (e.g., database credentials for a specific session). (3) Encryption key: used for data encryption at rest — rotated per schedule, old versions kept for decryption.

Rotacja (RotationEvent). Atrybuty: event_id, target (key_id / secret_path / certificate_serial), old_version, new_version, triggered_by (SCHEDULE / ADMIN / INCIDENT), triggered_at, completed_at, status (SUCCESS/FAILURE). Harmonogram rotacji: Root CA key: nigdy (20-year validity, wymiana = nowa ceremonia). Intermediate CA key: co 3 lata (lub per incident). Client IPsec cert: co 30 dni (auto). Workload mTLS cert: co 24h (auto). Service mTLS cert: co 30 dni (auto). Database password: co 90 dni (auto via Vault). API keys: co 90 dni (manual + notification). Incydent-triggered rotation: natychmiast po wykryciu kompromitacji klucza — emergency rotation procedure (documented runbook).

30.7 Asset, urządzenie, router, stan zgodności — model aktywów

Status: [N] Normatywny Odbiorca: Architekt | Infra | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 17.2, 27.1, 29.3, 30.1

Model aktywów (asset model) śledzi wszystkie fizyczne i logiczne zasoby pod zarządzaniem SYLION.

Encja: Device (Terminal). Atrybuty: device_id (UUID, generated at enrollment), type (PIXEL_MOBILE / MANAGED_LAPTOP / ROUTER), make_model (e.g., „Pixel 8 Pro”, „Lenovo ThinkPad T14s”), serial_number (hardware), os_type (GrapheneOS / Fedora Silverblue / NixOS), os_version, patch_level, encryption_status (FDE enabled: yes/no), fido2_enrolled (yes/no), ipsec_cert_serial, last_posture_check_at, posture_score (0–100), compliance_status (COMPLIANT / NON_COMPLIANT / UNKNOWN), assigned_operator_id, enrolled_at, last_seen_at. Lifecycle: (1) Enrolled: device registered, OS flashed, VPN configured, FIDO2 enrolled. (2) Active: device used by operator, posture checked regularly. (3) Non-compliant: posture score below threshold → operator notified, session restricted/blocked. (4) Decommissioned: device wiped (factory reset), enrollment revoked, device_id retained in audit log.

Encja: Router. Atrybuty: router_id, model (GLiNet Beryl AX / Flint 2), firmware_version, config_version, ipsec_config (pre-loaded VPN config), last_seen_at, compliance_status, assigned_to (operator / command center). Lifecycle: similar to Device. Router jest opcjonalny — nie wszyscy operatorzy używają dedykowanego routera.

Encja: Host (Server). Atrybuty: host_id, zone (Zone 2/3/4/5), role (G1/G2/WORKLOAD_NODE/SHARED_SERVICES/MANAGEMENT), make_model, serial_number, cpu_model, ram_gb, storage_tb, os_type (Flatcar / Talos / NixOS), os_version, patch_level, tee_capable (AMD SEV-SNP / Intel TDX / NONE), compliance_status, last_scan_at. Lifecycle: (1) Provisioned: hardware procured, OS installed (laC), roles assigned. (2) Active: running workloads/services. (3) Maintenance: scheduled patching (immutable update — reboot to new image). (4) Decommissioned: data erased (cryptographic), removed from laC, hardware returned/destroyed.

Encja: HSM. Atrybuty: hsm_id, type (ON_PREMISE / CLOUD_DEDICATED / SOFTWARE), vendor (Thales / nCipher / Utimaco / AWS / Azure / SoftHSM2), model, serial_number, firmware_version, fips_certification (FIPS 140-3 Level 3 / Level 2 / None), key_count (active keys), last_ceremony_date, last_firmware_update, tamper_status (OK / ALERT), ha_partner_id (HA pair). Lifecycle: (1) Initialized: HSM hardware installed, admin initialized, root CA key generated (ceremony). (2) Active: processing crypto operations. (3) Maintenance: firmware update (signed, dual custody). (4) Decommissioned: keys destroyed (zeroize command), hardware returned to vendor or physically destroyed.

Compliance status computation. Compliance status per asset: computed from weighted checks: OS version (current vs required), patch level (age of unpatched CVEs), encryption (FDE enabled), configuration (matches laC desired state), certificate (valid, not near expiry). Score: weighted average → threshold (>80 = COMPLIANT, 50–80 = DEGRADED, <50 = NON_COMPLIANT). Non-compliant assets → alert, potential session blocking.

30.8 Integracja, connector, kontrakt danych — model integracyjny

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner Wpływ na baseline: Średni Powiązane rozdziały: 17.5, 27.10, 30.1, 31.8

Model integracyjny definiuje, jak SYLION łączy się z systemami zewnętrznymi w sposób kontrolowany, wersjonowany i audytowalny.

Encja: Connector. Atrybuty: connector_id (UUID), tenant_id, type (IDP_OIDC / IDP_SAML / SIEM_SYSLOG / SIEM_SPLUNK / SIEM_SENTINEL / MDM_INTUNE / MDM_JAMF / WEBHOOK / CUSTOM_API), name (human-readable), endpoint (URL/IP), auth_method (CERTIFICATE / API_KEY / OAUTH2 / TOKEN), auth_credential_ref (Vault path to stored credentials), status (ACTIVE / PAUSED / ERROR / DISABLED), created_at, last_successful_sync_at, error_count (recent failures), error_last_message. Lifecycle: (1) Created: TENANT_ADMIN configures connector (endpoint, auth, event categories). (2) Tested: automated test (connectivity, auth, sample event delivery). (3) Active: operational. (4) Paused: TENANT_ADMIN pauses (e.g., maintenance on external system). (5) Error: persistent failures → auto-paused after threshold, alert to TENANT_ADMIN. (6) Disabled: TENANT_ADMIN deactivates or tenant offboarded.

Encja: DataContract. Kontrakt danych definiuje schema i SLA dla każdej integracji. Atrybuty: contract_id (UUID), connector_id, schema_version (semver), data_format (JSON / CEF / SAML assertion), fields (list of expected fields + types), sla_delivery_time (max seconds for event delivery), sla_availability (uptime % of external system — not SYLION's SLA, but expectation), retry_policy (max retries, backoff), ttl (max age of data before discard), validation_rules (regex/type checks on fields). DataContract jest wersjonowany: zmiana schematu = nowa wersja = migration plan.

Encja: IntegrationEvent. Każda interakcja z systemem zewnętrznym generuje IntegrationEvent. Atrybuty: event_id, connector_id, direction (OUTBOUND: SYLION → external / INBOUND: external → SYLION), payload_size_bytes, status (SUCCESS / FAILURE / TIMEOUT / RETRY), response_time_ms, error_details (if failure), timestamp. IntegrationEvents agregowane do metryk: success_rate per connector, avg_response_time, error_rate. Alert: jeśli error_rate > threshold (e.g., >5% in 15 min) → alert TENANT_ADMIN.

30.9 Model relacyjny wysokiego poziomu — diagram ERD (ASCII)

Status: [N] Normatywny Odbiorca: Architekt | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 30.1–30.8

Poniższy diagram ERD przedstawia kluczowe relacje między encjami modelu danych SYLION na najwyższym poziomie abstrakcji.

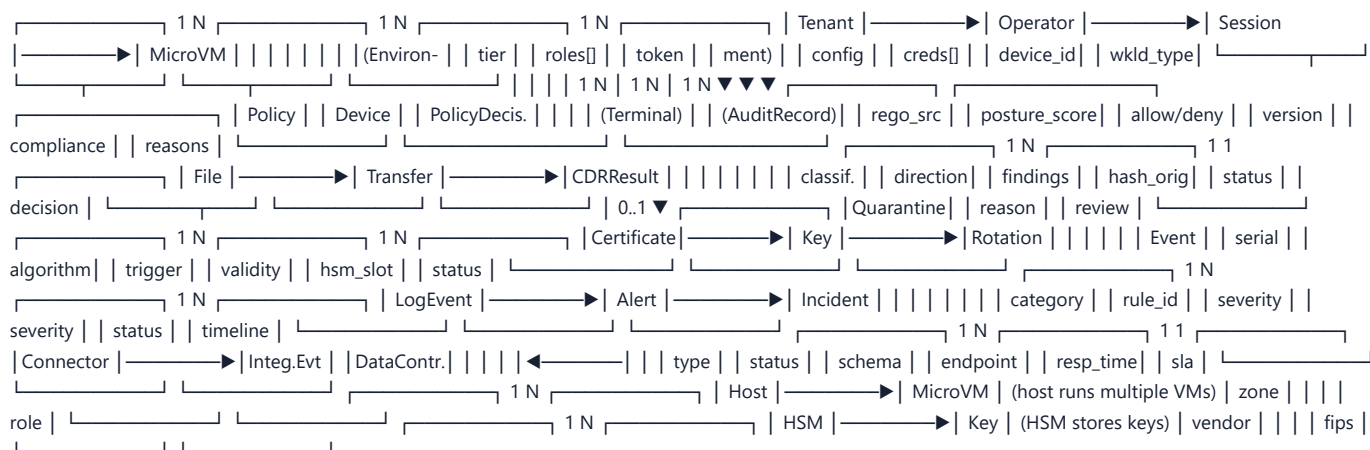


Diagram przedstawia kluczowe relacje: Tenant → Operator → Session → MicroVM (łańcuch operacyjny), File → Transfer → CDR → Quarantine (pipeline plikowy), Certificate → Key → Rotation (kryptografia), LogEvent → Alert → Incident (zdarzenia bezpieczeństwa), Connector → IntegrationEvent (integracje). Relacje nie

obrazują pełnego schematu bazy danych — to model konceptualny.

30.10 Granice i klasyfikacja danych — co jest wrażliwe, jak klasyfikowane, jak chronione

Status: [N] Normatywny Odbiorca: Architekt | Compliance | SOC | Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.3, 24.4, 25.1, 26.3, 30.1, 30.4

Klasyfikacja danych w SYLION definiuje poziomy wrażliwości, mechanizmy ochrony i reguły przepływu danych między strefami.

Poziomy klasyfikacji. (1) UNRESTRICTED: dane publiczne, nie wymagają ochrony poufności (np. publiczny certyfikat TLS G1, dokumentacja publiczna). (2) INTERNAL: dane wewnętrzne SYLION/klienta, nie przeznaczone do publikacji (np. konfiguracja sieciowa, metryki wydajności, lista operatorów). (3) CONFIDENTIAL: dane poufne wymagające ochrony (np. logi bezpieczeństwa, polityki OPA, konfiguracje integracji, API keys). (4) SECRET: dane wysoce poufne (np. klucze kryptograficzne, konfiguracja HSM, dane operatorów w tierze STATE). (5) TOP_SECRET: dane o najwyższej wrażliwości (np. root CA private key — przechowywany wyłącznie w HSM, nigdy nie eksportowany).

Klasyfikacja per zone. Zone 0 (Endpoint): INTERNAL (konfiguracja VPN, certyfikat klienta). Zone 1 (Access): CONFIDENTIAL (ruch zaszyfrowany, metadata routing). Zone 2 (Gateway): CONFIDENTIAL (session state, policy decisions, device posture). Zone 3 (Workloads): CONFIDENTIAL → TOP_SECRET (treść sesji operatora — klasyfikacja zależy od danych przetwarzanych przez operatora). Zone 4 (Shared Services): CONFIDENTIAL (logi, CDR staging, backup config). Zone 5 (Management): SECRET → TOP_SECRET (PKI, HSM, secrets, IaC state).

Mechanizmy ochrony per klasyfikacja.

	Klasyfikacja	Mechanizmy ochrony
	UNRESTRICTED	Brak specjalnych wymagań
INTERNAL	Encryption at rest, access control (RBAC)	
CONFIDENTIAL	+ encryption in transit (mTLS/IPsec), audit logging,	DLP on egress, per-tenant isolation
SECRET	+ HSM-backed keys, TEE (Confidential Computing),	dual custody for admin access, enhanced audit
TOP_SECRET	+ HSM only (no export ever), physical security,	air-gapped option, ceremony-based access

Przepływ danych między klasyfikacjami. Dane mogą przepływać „w dół” (SECRET → CONFIDENTIAL — z explicit declassification by admin) lub „również” (SECRET → SECRET). Dane nie mogą przepływać „w górę” bez re-klasyfikacji: plik INTERNAL nie staje się SECRET przez przeniesienie do Zone 3 — ale plik tworzony w Zone 3 w sesji operatora z clearance SECRET dziedziczy klasyfikację SECRET.

Labeling. W tierze STATE/SOVEREIGN: klasyfikacja jest explicit (każdy plik, dokument, pokój Matrix ma etykietę). W tierach STANDARD/PRO: klasyfikacja jest implicit (wszystkie dane traktowane jako CONFIDENTIAL default, bez explicit labeling). Explicit labeling: enforcement przez Policy Engine (operator z clearance INTERNAL nie może otworzyć dokumentu SECRET) + visual indicator (label wyświetlany w UI workloadu).

Rozdział 31. Mapy przepływu informacji i integracji

31.1 Przepływ operatora (logowanie → sesja → wylogowanie) — szczegółowy flow diagram

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 24.2, 25.4, 27.1–27.5, 29.5, 30.2

Przepływ operatora opisuje pełny cykl od momentu uruchomienia terminala do zakończenia pracy. Każdy krok jest obowiązkowy — pominięcie dowolnego kroku skutkuje odmową dostępu.

Faza 1: Zestawienie transportu (Terminal → G1).

Terminal G1 G2 | | | — IKEv2 IKE_SA_INIT → | | | ← IKE_SA_INIT resp — | | | — IKE_AUTH (cert) → | | | (X.509 client cert) — CRL/OCSP check → PKI | | | ← cert valid — | | | ← IKE_AUTH resp — | | | (tunnel established) | | | | [Kill switch: all non-IPsec traffic blocked] | |

Czas: 200–500ms (zależny od latencji sieci). Jeśli certyfikat odwołany → G1 odrzuca IKE_AUTH → brak tunelu → operator widzi „Connection refused”.

Faza 2: Uwierzytelnienie (Terminal → G2 via G1).

Terminal G1 G2 Keycloak | | | — HTTPS /auth/login → | — forward → | | | — OIDC authz → | | | ← redirect to IdP — | | | — FIDO2 challenge → | — forward → | | | (YubiKey tap) | — verify → | | | ← token — | | | — device posture | | | evaluation | | | | — policy eval | | | (OPA) | | | | ← session token (JWT) — | | | —

Czas: 1–5s (FIDO2 tap + IdP round-trip + policy evaluation). Jeśli device posture < threshold → access denied. Jeśli policy deny → session refused z reason code.

Faza 3: Uruchomienie workloadów (G2 → Orchestrator → MicroVMs).

G2/Session Broker Orchestrator MicroVMs | | | — start_session —————→ | | | (operator_id, — create env-matrix ► boot <150ms | workload_set, — create env-browser ► boot <150ms | resource_profile) — create env-voice —————→ boot <150ms | | | — health check —————→ ready | ← session_ready ————— | | | (workload_endpoints) | |

Czas: 300–800ms (parallel boot). Session broker mapuje workload endpoints → terminal pixel streaming.

Faza 4: Aktywna sesja.

Terminal G1/G2 Session Broker Workloads | | | | ← pixel stream (continuous) —————→ | | | ← audio stream —————→ | | | | | heartbeat | | | every 30s | | | | ← re-evaluate | | | policy (5min) | | | ————— | |

Continuous: pixel + audio stream. Periodic: heartbeat (30s), policy re-evaluation (5min), device posture re-check (5min).

Faza 5: Zakończenie sesji.

Terminal G2/Session Broker Orchestrator Workloads | | | | — logout request —————→ | | | | — revoke token | | | — stop session ► | | | | — ACPI shutdown ► | | | (wait 10s) | | | — force kill —————→ | | | — destroy VM | | | — erase storage | | | — destroy netns | | | ← session_ended ————— |

| | | | | — IKEv2 DELETE —————> G1 | | | (tunnel teardown) | | |

Czas: <30s od logout request do pełnego cleanup. Token revoked <5s. MicroVMs destroyed <15s. Storage erased <1s (cryptographic erase).

31.2 Przepływ sesji (zestawienie → utrzymanie → zakończenie) — z timeoutami i heartbeat

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 27.4, 29.5, 30.2, 31.1

Przepływ sesji opisuje mechanikę session brokera w zarządzaniu cyklem życia sesji, ze szczegółami timeout i heartbeat.

Zestawienie sesji — timeline.

T+0.0s Operator submits credentials (FIDO2 tap) T+0.5s Keycloak verifies FIDO2 assertion, issues OIDC token T+0.7s G2 receives token, fetches device posture attributes T+0.8s G2 evaluates OPA policy (input: identity + posture + context) T+0.9s Policy: ALLOW (with obligations: clipboard=text-only) T+1.0s Session broker creates session record (session_id, token, metadata) T+1.1s Session broker → orchestrator: start workloads T+1.3s Orchestrator boots microVMs (parallel) T+1.5s Health checks pass, session broker notified T+1.6s Session broker → terminal: session_ready (workload endpoints) T+1.8s Terminal connects to pixel stream → operator sees workspace

Total login time: ~2 sekund (best case). Acceptable: <5 sekund. Degraded: 5–10 sekund (network latency). Unacceptable: > 10 sekund (investigation required).

Utrzymanie sesji — mechanizmy.

Heartbeat. Terminal → session broker: heartbeat every 30s (configurable: 15–60s). Payload: session_id, timestamp, terminal_uptime, network_quality (RTT, packet_loss). Missed heartbeat: 1 miss → no action (transient network issue). 2 consecutive misses (60s) → session marked DEGRADED, alert to SOC. 3 consecutive misses (90s) → session terminated (assumed disconnect). Heartbeat response: session broker → terminal: session_status (ACTIVE/IDLE_WARNING), obligations_update (if policy changed).

Policy re-evaluation. Session broker re-evaluates policy every 5 minutes (configurable: 1–15 min). Re-evaluation input: current identity + current device posture + current context (time may have changed, risk_score may have changed). Possible outcomes: (a) ALLOW continues → no action. (b) ALLOW with new obligations → obligations updated (e.g., session recording enabled due to elevated risk). (c) DENY → session terminated with reason „policy violation: [details]”.

Token refresh. JWT token expires after 1h (configurable: 30min–4h). Silent refresh: session broker issues new token 5 minutes before expiry. Operator does not see refresh. If refresh fails (Keycloak unavailable): session continues with current token for grace period (15 min), then terminated.

Idle detection. No operator input (keyboard/mouse/touch) for idle_timeout period. Default: 15 min (desktop), 5 min (mobile). Action: (a) Warning at idle_timeout - 2 min (operator sees „Session idle — will disconnect in 2 min”). (b) Termination at idle_timeout. (c) Configurable per policy: disable idle timeout (not recommended), extend timeout, require re-auth on resume.

Zakończenie sesji — triggers i cleanup.

Triggers: (1) Operator logout (voluntary). (2) Admin revocation (TENANT_ADMIN or PLATFORM_ADMIN revokes session). (3) Idle timeout. (4) Max session duration (8h default). (5) Policy violation (device posture drop, failed re-evaluation). (6) Heartbeat loss (3 consecutive misses). (7) Token expiry without refresh. (8) Infrastructure failure (host crash — session broker detects via orchestrator health check).

Cleanup sequence: patrz 31.1 Faza 5. Additional: session record updated (end_time, duration, termination_reason), AuditRecord created, metrics updated (session_count, avg_duration).

31.3 Przepływ pliku (upload → staging → CDR → delivery → audit) — krok po kroku

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 26.10, 27.6, 30.4

Przepływ pliku opisuje pełny pipeline przetwarzania pliku od momentu uploadu do dostarczenia lub kwarantanny.

Operator Workload G2/CDR CDR CDR Workload Terminal (source) Trigger Orchestrator MicroVM (destination) | | | | | — upload —————> | | | | | — file —————> | | | | | — stage —————> | | | | | (encrypt, | | | | | hash, | | | | | classify) | | | | | — create —————> | | | | | — ephemeral | | | | | microVM | | | | | — send —————> | | | | | file — parse | | | | | — disarm | | | | | — reconstr. | | | | | — validate | | | | | — result —————> | | | | | — destroy | | | | | microVM | | | | | — CDR | | | | | result | | | | | | | | [CLEAN] | | | | | — deliver —————> | | | | | [QUARANTINE] | | | | | — move to quarantine | | | | | — alert operator | | | | | — audit log | | | | | — notification | | | | |

Szczegóły kroków:

Krok 1: Upload (T+0ms). Operator uploaduje plik z terminala (drag & drop lub file picker w workload UI). Plik przechodzi przez session protocol (pixel streaming channel → workload) → workload przekazuje do G2/CDR trigger.

Krok 2: Staging (T+50ms). G2/CDR trigger: (a) generuje file_id (UUID), (b) oblicza hash_original (SHA-256), (c) identyfikuje format (libmagic — deep file type detection), (d) weryfikuje rozmiar (max 100MB default, configurable per policy), (e) zapisuje do CDR staging storage (Zone 4, encrypted AES-256, per-file key). Jeśli rozmiar > max → reject + alert.

Krok 3: CDR Processing (T+200ms → T+30s). CDR orchestrator: (a) pobiera plik ze staging, (b) tworzy efemeryczną microVM CDR (Firecracker, boot <150ms, pre-warmed pool), (c) wysyła plik do microVM. MicroVM CDR: (d) parsuje plik (format-specific parser), (e) disarm: usuwa active content (macros, scripts, embedded objects, OLE links), (f) strips metadata (author, GPS, revision history — configurable per policy), (g) reconstructs: buduje czysty dokument od zera, (h) validates: sprawdza poprawność zrekonstruowanego dokumentu, (i) oblicza hash_reconstructed.

Krok 4: Decision (T+30s). CDR orchestrator: (a) jeśli CLEAN → deliver, (b) jeśli processing error → QUARANTINE + alert, (c) jeśli unsupported format → QUARANTINE + alert, (d) jeśli suspicious (heuristic detection of evasion) → QUARANTINE + alert.

Krok 5: Delivery (T+31s). Zrekonstruowany plik przesyłany do workloadu docelowego (Zone 3). Plik dostępny dla operatora.

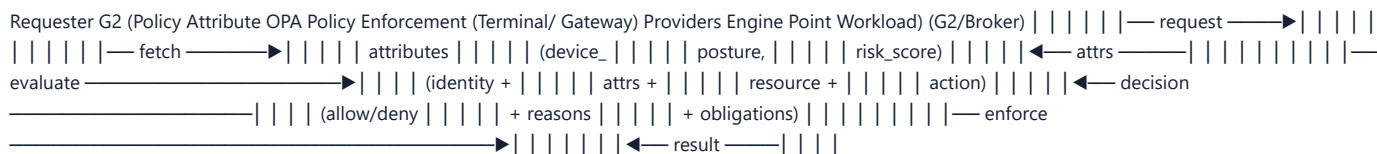
Krok 6: Audit (T+32s). AuditRecord: file_id, transfer_id, hash_original, hash_reconstructed, format, size, CDR findings (what was removed), decision, processing_time_ms, microvm_id, timestamps.

Krok 7: Cleanup (T+33s). Staging storage: plik usunięty. CDR microVM: zniszczona. Quarantine (jeśli applicable): oryginał przechowywany w encrypted quarantine storage (retention per policy).

31.4 Przepływ decyzji polityk (request → policy eval → decision → enforcement) — latency budgets

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 27.8, 27.9, 29.3, 30.3

Przepływ decyzji polityk jest najczęstszą operacją w runtime SYLION — wykonywany przy każdym loginie, co 5 minut (re-evaluation), przy każdym transferze pliku i przy każdej zmianie kontekstu.



Latency budget (end-to-end target: <50ms).

	Krok	Target	Max	
Request parsing	1ms	5ms	Attribute fetch	5ms 15ms - device posture (cache) 1ms 5ms - risk score (cache) 1ms 5ms - identity (JWT decode) 2ms 5ms OPA evaluation 5ms 20ms Decision logging 2ms 5ms Enforcement action 2ms 5ms Response to requester 1ms 5ms
TOTAL	16ms	50ms		

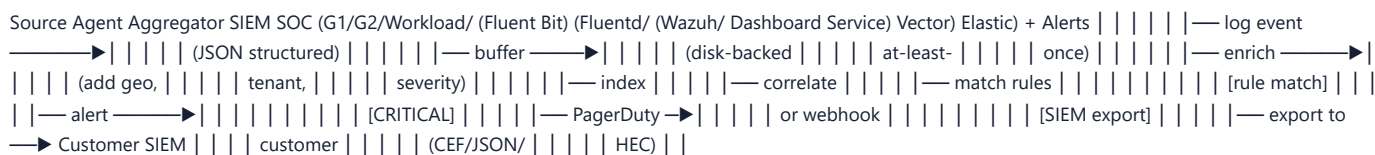
Fallback behavior. Jeśli OPA Policy Engine jest niedostępny (crash, network partition): G2 używa local policy cache (last-known-good policies, max staleness: 15 min). Jeśli cache stale > 15 min: fail-closed (all access denied, alert CRITICAL). Jeśli attribute provider (Keycloak, SIEM) jest niedostępny: use cached attributes + decrease confidence score → more restrictive policy (conservative decision).

Re-evaluation flow. Co 5 minut session broker triggers re-evaluation: (1) fetch fresh attributes, (2) evaluate against current policies, (3) if decision changed (allow → deny, or new obligations): (a) deny → terminate session, (b) new obligations → update session (e.g., enable recording). Re-evaluation is transparent to operator (no visible interruption if still allowed).

31.5 Przepływ logów (event → collector → SIEM → alert → ticket)

Status: [N] Normatywny Odbiorca: Architekt | SOC | Infra Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.4, 27.6, 27.7, 30.5, 31.6

Przepływ logów opisuje drogę zdarzenia od momentu powstania do alertu i potencjalnego ticketa.



Timeline.

T+0ms Event generated (source component) T+1ms Event written to Fluent Bit buffer (local) T+100ms Fluent Bit forwards to aggregator (batch, <100ms) T+200ms Aggregator enriches (geo, tenant mapping) T+500ms SIEM ingests, indexes T+1s SIEM evaluates correlation rules T+2s Alert generated (if rule matches) T+5s Alert visible on SOC dashboard T+60s MAX acceptable delay (source → SIEM)

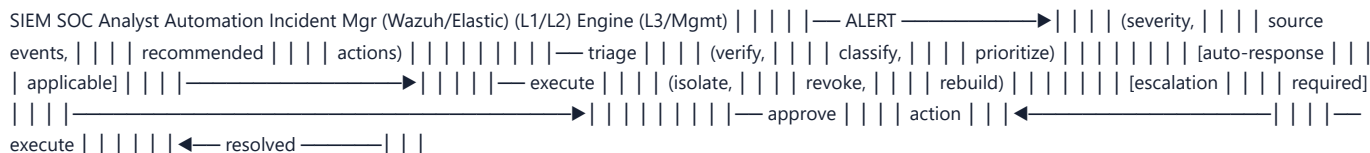
SLA: source → SIEM ingest < 60 sekund. source → SOC alert < 120 sekund. Monitoring: pipeline health dashboard (Fluent Bit throughput, aggregator lag, SIEM ingest rate). Alert on pipeline degradation (lag > 30s → WARN, lag > 60s → CRITICAL).

Categories exported to customer SIEM. Per-tenant configuration: session events (login/logout/timeout), policy decisions (allow/deny), CDR events (accept/quarantine), admin operations (provisioning/config change), infrastructure alerts (optional). Customer SIEM export lag: additional 10–30s (network to customer SIEM endpoint). Buffer: 72h in Zone 4 (retransmit on customer SIEM recovery).

31.6 Przepływ alertów (trigger → triage → escalation → response)

Status: [N] Normatywny Odbiorca: SOC | Architekt | Zarząd Wpływ na baseline: Wysoki Powiązane rozdziały: 17.4, 27.7, 30.5, 31.5

Przepływ alertów opisuje proces od wygenerowania alertu przez SIEM do podjęcia działań korygujących.



Severity matrix i SLA.

	Severity	Opis	Response SLA	Resolution
boundary violation, HSM tamper	CRITICAL	Active breach,	<15 min	<1h Zone
HIGH Failed auth burst, <1h <4h CDR repeated		quarantine, drift		detected
MEDIUM Device posture		<4h <24h		degraded,
cert near expiry, unusual login pattern				

needed, | | | | capacity warning | | | | LOW | Informational, | <24h | <7d | | maintenance

Auto-response (pre-approved playbooks). Wybrane alerty mają pre-approved auto-response: (a) „5 failed logins from same IP” → temporary IP block (15 min). (b) „Device posture score < 30” → session termination. (c) „Drift detected on Zone 3 host” → automatic rollback (GitOps reconciliation). (d) „Certificate expired” → automatic renewal trigger (Vault). Auto-response jest ograniczone do pre-approved playbooks — destructive actions (rebuild host, revoke all sessions for tenant) wymagają manual approval (dual authorization).

31.7 Przepływ backupów (config capture → encrypt → store → verify → test restore)

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 17.4, 27.6, 28.9, 29.8, 30.6

Przepływ backupów obejmuje zabezpieczenie konfiguracji platformy — nie danych operacyjnych (workloady są efemeryczne).

Source Backup Agent Backup Storage Verification (Terraform state, (Restic) (S3/MinIO, Engine OPA policies, encrypted) Keycloak export, cert metadata) | | | | — export —> | | | | (scheduled: | | | | daily increm., | | | | weekly full) | | | | — encrypt —> | | | | (Restic AES- | | | | 256-CTR + | | | | Poly1305) | | | | — replicate —> | | | | to secondary | | | | region | | | | — verify | | | | integrity | | | | (checksum, | | | | decrypt | | | | test) | | | | [monthly] | | | | — test | | | | restore | | | | (isolated | | | | env)

Zakres backupu.

	Dane	Backup?	Uwagi
backend	OPA policies	TAK	Git repo (primary) + Restic
	Keycloak realm config	TAK	Export (JSON), encrypted
	Vault config (not keys)	TAK	Vault snapshot, encrypted
	Certificate metadata	TAK	Serial, validity, but NOT
	private keys		Log data
	TAK		Replicated to secondary
	HSM keys		HSM keys
	NIE (*)		HSM backup via ceremony only
	Workload ephemeral data	NIE	Efemeryczne — nie backupowane
	Session content	NIE	E2E encrypted, efemeryczne
	Operator documents	OPCJONALNIE	Per-tenant policy

(*) HSM keys: backup wyłącznie przez ceremonialne procedury (M-of-N key custodian quorum, physical media, secured storage). Nie uczestniczą w automated backup pipeline.

Harmonogram. Daily: incremental backup (changed files since last backup). Weekly: full backup (all files). Retention: 30 days rolling (daily snapshots) + 12 monthly snapshots (first backup of each month). Replication: async to secondary region (<1h lag).

Weryfikacja. Daily: automated checksum verification (Restic check). Monthly: automated test restore to isolated environment (deploy from backup to test namespace, verify: Terraform plan shows no changes, Keycloak login works, OPA evaluates correctly). Quarterly: manual DR drill (full restore + operator acceptance test). Report: każda weryfikacja generuje Backup Verification Report (timestamp, scope, result, issues, remediations).

31.8 Przepływ integracji zewnętrznych (API auth → request → response → audit)

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Partner Wpływ na baseline: Średni Powiązane rozdziały: 17.5, 27.10, 29.9, 30.8

Przepływ integracji zewnętrznych opisuje jak systemy klienta komunikują się z SYLION przez Management API.

Customer API Gateway Auth Service Backend Audit System (Kong/Envoy) (OAuth 2.0) Service Log | | | | — OAuth token —> | | | | request | — validate | | | | (client_creds | token —> | | | | flow) | — verify | | | | — valid —> | | | | signature | | | | + claims | | | | + scope | | | | — API request —> | | | | (mTLS + Bearer | — rate | | | | token) | limit —> | | | | check | | | | — route —> | | | | — process | | | | request | | | | — log —> | | | | — response —> | | | | (JSON + status | | | | + request_id) | | | |

Uwierzytelnianie API. (1) mTLS: wymagane — klient przedstawia certyfikat klienta wydany przez SYLION lub zaufane CA. Certyfikat weryfikowany na API Gateway (subject, issuer, validity, CRL check). (2) OAuth 2.0: Bearer token uzyskany przez client_credentials flow (dla automatyzacji) lub authorization_code flow (dla interakcji administracyjnych). Token scope: definiuje dozwolone operacje (read:operators, write:policies, admin:tenant).

Rate limiting. Per tenant: 100 req/min (STANDARD), 500 req/min (PRO), 1000 req/min (STATE/SOVEREIGN). Per API key: 50 req/min. Exceeded: HTTP 429 Too Many Requests + Retry-After header. Burst: 2x limit for 10s.

Error handling. Standard HTTP codes: 200 (OK), 201 (Created), 400 (Bad Request), 401 (Unauthorized), 403 (Forbidden — valid auth but insufficient scope), 404 (Not Found), 429 (Rate Limited), 500 (Internal Error). Error response body: { error_code, message, details, request_id }. request_id: unique per request, used for troubleshooting (customer provides request_id to support).

Audit. Każdy API request generuje AuditRecord: timestamp, client_id (from certificate/token), action (HTTP method + path), target (resource ID), result (HTTP status), response_time_ms, source_ip. AuditRecords dostępne dla TENANT_ADMIN (own tenant) i AUDITOR.

31.9 Przepływ provisioning (request → approval → IaC → deploy → test → handoff)

Status: [N] Normatywny Odbiorca: Architekt | Infra | Dev | Partner Wpływ na baseline: Wysoki Powiązane rozdziały: 17.4, 24.2, 27.5, 27.7, 29.1, 29.9, 30.2

Przepływ provisioning opisuje proces od zgłoszenia potrzeby dodania nowego operatora do momentu, gdy operator może rozpocząć pracę.

TENANT_ADMIN Provisioning IaC Pipeline Orchestrator Operator (or API) Engine (Terraform/ (Zone 3) (New) | | Ansible | | — request —> | | | | (operator | | | | details, | | | | role, | | | | workload_ | | | | set) | | | | — validate | | | | (quota, | | | | license, | | | | policy) | | | | — Step 1: —> | | | | IAM | | | | (Keycloak: | | | | create user, | | | | assign role) | | | | — Step 2: —> | | | | VPN | | | | (issue cert, | | | | configure | | | | VPN profile) | | | | — Step 3: —> | | | | Workload env | | | | (create | — create | | | | namespace, | namespace, | | | | pre-pull | pre-pull | | | | images) | images | | | | — Step 4: —> | | | | Policies | | | | (OPA bundle | | | | update) | | | | — Step 5: —> | | | | Smoke test | — test boot | — | — test session— | | | | — test CDR — | | | | — Step 6: | | | | FIDO2 enrollment | | | | (generate | | | | enrollment | — enroll —> | | | |

```

link | FIDO2 key | | | | ← complete — | | | (operator_id, | | | login_url, | | | VPN_config) | | | | | | | | | | ← handoff — |
| | | (terminal | | | config'd, | | | first | | | login OK)

```

Saga pattern. Provisioning jest realizowany jako orchestrated saga: każdy krok jest transakcją z compensating action. Jeśli Step 3 (workload env) fails: compensating actions = (1) destroy VPN config (Step 2 compensation), (2) delete IAM user (Step 1 compensation). Saga gwarantuje: pełny provisioning (all steps complete) lub pełny rollback (no partial state).

Timeline. Step 1 (IAM): 5–15s. Step 2 (VPN): 10–30s. Step 3 (Workload env): 30–120s. Step 4 (Policies): 5–10s. Step 5 (Smoke test): 30–60s. Step 6 (FIDO2): 1–5 minut (wymaga interakcji operatora). Total automated: <4 minut. Total z FIDO2: <10 minut. Target SLA: <4 godziny end-to-end (w tym manual steps: terminal setup, physical verification).

31.10 Przepływ offboarding (trigger → revoke → archive → destroy → evidence)

Status: [N] Normatywny Odbiorca: Architekt | Infra | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 17.2, 17.4, 27.5, 27.9, 30.2, 31.9

Przepływ offboarding opisuje proces usunięcia operatora z platformy — od momentu podjęcia decyzji do zakończenia i udokumentowania. Offboarding musi zamknąć się w 15 minut (target).

TENANT_ADMIN Offboarding IAM Session Orchestrator (or API / Engine (Keycloak) Broker (Zone 3) automated) | | | | — offboard —> | | | |
(operator_id, | | | | reason, | | | | immediate?) | | | | | — Step 1: —> | | | | Revoke — disable | | | | identity | user | | | | —
revoke | | | | FIDO2 creds | | | | — revoke | | | | OIDC tokens | | | | | — Step 2: —————> | | | | Terminate | —
terminate | | | | sessions | all active | | | | sessions | | | | | — Step 3: —————> | | | | Revoke | — revoke | | | | VPN/certs
| | IPsec cert | | | | (CRL update) | | | | | — Step 4: —————> | | | | Destroy | | | | workloads | —
destroy | | | | all microVMs | | | | — erase | | | | persistent | | | | storage | | | | — destroy | | | | namespace | | | | | — Step 5: | |
| | | | Archive | | | | (audit logs | | | | retained, | | | | operator | | | | record | | | | archived) | | | | | — Step 6: | | | | Evidence |
| | | | (generate | | | | offboard | | | | report) | | | | | — complete — | | | | (offboard | | | | report URL) | | | |

Timeline. Step 1 (Revoke identity): <5s. Step 2 (Terminate sessions): <30s. Step 3 (Revoke VPN/certs): <30s (CRL update propagation). Step 4 (Destroy workloads): <60s (microVM kill + storage erase). Step 5 (Archive): <60s (log retention flags, record status update). Step 6 (Evidence): <30s (generate report). Total: <3 minutu (automated). Target: <15 minut end-to-end.

Offboarding report. Generowany automatycznie: operator_id, tenant_id, offboarding_timestamp, reason, steps_executed (with timestamps), artefacts_destroyed (microVMs, storage, namespace, certificates), artefacts_retained (audit logs — per retention policy), confirmation (all credentials revoked: yes/no). Raport podpisany kryptograficznie (HSM-backed signature), przechowywany w audit log.

Emergency offboarding. Trigger: TENANT_ADMIN urgent request, security incident, compromised credential. Procedura: Step 1 + Step 2 wykonywane jednocześnie (revoke + terminate — nie czekaj na zakończenie Step 1 przed Step 2). Target: credential revoked + session terminated < 30 sekund.

31.11 Przepływ komunikacji głosowej i mediów (call setup → media routing → encryption → teardown)

Status: [N] Normatywny Odbiorca: Architekt | Dev | Infra Wpływ na baseline: Wysoki Powiązane rozdziały: 17.2, 24.2, 26.11, 27.5, 30.2

Przepływ komunikacji głosowej opisuje pełny cykl rozmowy głosowej (1:1 lub grupowej) między operatorami tego samego tenanta.

```

sequenceDiagram
    participant OA as Operator A
    participant OB as Operator B
    participant S as Server (Workload B)

    OA->>OB: SIP
    OB->>S: RTP
    S->>OB: ring
    OB->>S: negotiate
    S->>OB: DTLS key exchange
    OA->>OB: MEDIA
    OB->>S: audio
    S->>OB: audio
    OA->>OB: hangup
    OB->>S: BYE
    S->>OB: audit log
  
```

Sygnalizacja (Control Plane). Protokół: SIP (Session Initiation Protocol) lub Matrix VoIP signaling (MSC2746). Routing: signaling przechodzi przez Matrix homeserver (env-matrix) lub dedicated SIP server (env-voice). Signaling jest szyfrowany (mTLS between workloads ↔ media server).

Media (Media Plane). Protokół: SRTP (Secure Real-time Transport Protocol) z DTLS-SRTP key exchange. Codec: Opus (48kHz, VBR, 20ms frames — optimized for speech). Bitrate: 24–64 kbps per stream (adaptive, depends on network quality). Jitter buffer: 50–200ms (adaptive). Media routing: (1) 1:1 calls: peer-to-peer within Zone 3 (media flows directly between env-voice workloads, or via TURN relay if direct connectivity unavailable). (2) Group calls: media server (Jitsi Videobridge / LiveKit SFU) in Zone 3 per tenant. SFU (Selective Forwarding Unit): nie dekoduje mediów — forwarduje encrypted streams (end-to-end encryption maintained).

Zaryfrowanie. (1) Transport: SRTP (AES-128-GCM or AES-256-GCM, negotiated via DTLS). (2) E2E (opcjonalnie, STATE/SOVEREIGN): Insertable Streams / SFrame — operator endpoints encrypt media before sending to SFU, SFU forwards without decryption, receiving endpoints decrypt. Gwarancja: even media server (Jitsi/LiveKit) cannot access plaintext audio.

Quality of Service. Latency target: <150ms one-way (for acceptable conversational quality). Packet loss tolerance: <3% (Opus codec handles 5% with FEC). QoS marking: DSCP EF (Expedited Forwarding) for media packets within Zone 3 network. Monitoring: MOS (Mean Opinion Score) estimation from RTCP statistics → if MOS < 3.5 → alert (quality degradation).

Audit. Call metadata logged: call_id, initiator, participants, start_time, end_time, duration, codec, avg_bitrate, packet_loss_rate, MOS_estimate. Call content (audio): NOT logged (E2E encrypted, SYLION has no access to plaintext). Exception: if session recording enabled (STATE/SOVEREIGN, with consent) — audio recorded at workload level (before E2E encryption in non-E2E mode, or not recordable in E2E mode). # CZĘŚĆ V — MODUŁY SYSTEMOWE I SZCZEGÓŁOWE SPECYFIKACJE

Wersja dokumentu: 3.0.0-draft Data: 2026-04-05 Klasyfikacja: POUFNE — do użytku wewnętrznego Zakres: Rozdziały 32–51 — pełna specyfikacja modułów systemowych platformy SYLION

CZĘŚĆ V — MODUŁY SYSTEMOWE I SZCZEGÓŁOWE SPECYFIKACJE

Rozdział 32. Endpointy operatorskie i polityki terminali

32.1. Rola terminala w architekturze SYLION

Status: [N] Normatywny Odbiorca: Architekt, Administrator, Operator Wpływ na baseline: Krytyczny Powiązane rozdziały: 33.1, 37.1, 38.1

W architekturze SYLION terminal pełni rolę urządzenia wyświetlającego — cienkiego klienta (Thin Client), którego jedynym zadaniem jest renderowanie strumienia pikseli i dźwięku przesyłanego z chmurowego środowiska operatora. Terminal nie przechowuje danych roboczych, nie wykonuje logiki biznesowej i nie ma bezpośredniego dostępu do zasobów organizacyjnych. Wszystkie operacje odbywają się w izolowanych środowiskach (env-*) działających na infrastrukturze chmurowej, a terminal jedynie prezentuje ich obraz.

Założenie to jest fundamentalne dla całego modelu bezpieczeństwa SYLION. Utrata lub kompromitacja terminala nie oznacza wycieku danych, ponieważ na urządzeniu nie rezydują żadne dokumenty, klucze szyfrujące sesji ani artefakty robocze. Jedyne dane wrażliwe na terminalu to: materiał kryptograficzny do ustanowienia tunelu IPsec IKEv2 (chroniony przez Secure Element / TEE), token sesji (krótkotrwały, odnawiany), oraz profil MDM.

Architektura Thin Client wymaga stałego połączenia sieciowego — terminal musi utrzymywać tunel IPsec przez router dostępowy (Rozdział 33) do bramy G1 (Rozdział 35), a następnie uzyskać sesję streamingową przez Session Broker (Rozdział 37). Bez aktywnego połączenia terminal nie jest w stanie wykonać żadnej operacji roboczej, co jest świadomym kompromisem projektowym — priorytetem jest bezpieczeństwo i kontrola nad danymi, nie zaś tryb offline.

Terminal musi spełniać wymagania baseline compliance (32.14) obejmujące: szyfrowanie pamięci masowej, aktualny firmware, aktywny profil MDM, blokadę bootloadera oraz obecność klucza FIDO2. Weryfikacja zgodności odbywa się na poziomie G2 (Rozdział 36) przed każdym dopuszczeniem do sesji.

W modelu SYLION rozróżniamy trzy kategorie terminali: (a) terminal referencyjny — Google Pixel z profilem roboczym, (b) terminal desktopowy — laptop/PC z dedykowanym klientem, (c) terminal awaryjny — dowolne urządzenie z przeglądarką (ograniczony zakres funkcji, tier STANDARD wyłącznie). Każda kategoria podlega odrębnym politykom opisanym w podrozdziałach 32.2–32.4.

32.2. Pixel jako terminal referencyjny

Status: [N] Normatywny Odbiorca: Architekt, Administrator, Operator Wpływ na baseline: Krytyczny Powiązane rozdziały: 32.1, 32.5, 44.11

Google Pixel jest terminalem referencyjnym platformy SYLION. Wybór ten wynika z kilku kluczowych czynników: (a) Pixel oferuje najszybsze i najdłuższe wsparcie aktualizacji bezpieczeństwa wśród urządzeń Android — minimum 7 lat dla modeli od Pixel 8; (b) Titan M2 Secure Element zapewnia sprzętową ochronę kluczy kryptograficznych i atestacji urządzenia; (c) Verified Boot z blokadą bootloadera gwarantuje integralność systemu; (d) Android Work Profile umożliwia izolację środowiska roboczego SYLION od danych osobistych operatora.

Specyfikacja referencyjnego terminala Pixel: - Model minimalny: Pixel 8 lub nowszy (wymagany Titan M2, Android 14+) - Cena referencyjna: 900 € (w zestawie hardware kit) - Pamięć masowa: min. 128 GB, pełne szyfrowanie AES-256 (File-Based Encryption) - Sieć: Wi-Fi 6E, 5G (modele z modemem), Bluetooth 5.3 (wyłączony domyślnie) - Biometria: czytnik linii papilarnych (pod ekranem) — używany wyłącznie do odblokowania urządzenia, nie do uwierzytelnienia SYLION - Klucz FIDO2: zewnętrzny, biometryczny (200 €, osobny komponent zestawu)

Profil robocze SYLION musi być wdrożony za pośrednictwem systemu MDM/EMM (32.5). Profil zawiera: klienta VPN (IPsec IKEv2), klienta sesji streamingowej, aplikację uwierzytelniającą oraz polityki bezpieczeństwa. Operator nie powinien instalować na profilu roboczym żadnych aplikacji spoza listy dopuszczonych (whitelist — 32.6).

Odporność GrapheneOS na ekstrakcję forensic. W wyciekach kompatybilności narzędzi Cellebrite (kwiecień 2024, luty 2025, październik 2025) GrapheneOS konsekwentnie figuruje jako „niedostępny” do ekstrakcji zarówno w trybie BFU (Before First Unlock), jak i AFU (After First Unlock). Jest to jedyny mobilny system operacyjny z takim statusem. Dla porównania: stock Android i iOS w trybie AFU są oznaczone jako „dostępne” lub „częściowo dostępne” w tych samych dokumentach. Ta empiryczna odporność na najszerzej stosowane narzędzia forensic stanowi kluczowe uzasadnienie wyboru GrapheneOS jako terminala referencyjnego SYLION.

Pixel jako terminal referencyjny oznacza, że wszystkie procedury wdrożeniowe, playbooki konfiguracyjne i scenariusze testowe są opracowywane i walidowane w pierwszej kolejności na tym urządzeniu. Inne terminale mobilne mogą być dopuszczone (32.3), ale wymagają dodatkowej walidacji i mogą nie obsługiwać pełnego zakresu funkcji atestacji sprzętowej.

Na terminalu Pixel obowiązuje polityka automatycznych aktualizacji systemu — aktualizacje bezpieczeństwa muszą być instalowane w ciągu 72 godzin od publikacji. Administrator może wymusić aktualizację przez MDM. Brak zainstalowanej krytycznej aktualizacji skutkuje odmową sesji na poziomie G2.

32.3. Desktop/laptop jako terminal równoważny

Status: [N] Normatywny Odbiorca: Architekt, Administrator, Operator Wpływ na baseline: Wysoki Powiązane rozdziały: 32.1, 32.5, 33.1

Terminal desktopowy (laptop lub PC) jest w architekturze SYLION traktowany jako terminal równoważny — pełni identyczną rolę cienkiego klienta co Pixel, ale w formie dedykowanej aplikacji na systemie operacyjnym stacjonarnym. Dopuszczalne systemy operacyjne to: (a) Linux z hardened profilem (preferowany — Ubuntu 24.04 LTS lub Fedora Silverblue z immutable rootfs), (b) macOS 14+ z włączonym FileVault 2 i SIP, (c) Windows 11 Pro/Enterprise z BitLocker i Secure Boot.

W przypadku terminala desktopowego klient SYLION działa jako aplikacja okienkowa, która nawiązuje połączenie przez tunel IPsec (router dostępowy lub klient systemowy strongSwan) i renderuje strumień pikseli z Session Broker. Klient desktopowy musi implementować: blokadę schowka systemowego (clipboard isolation), blokadę przechwytywania ekranu (screen capture prevention — najlepsza możliwa ochrona na danym OS), oraz blokadę przekierowania plików (file redirect disabled domyślnie).

Wymagania baseline dla terminala desktopowego: - Pełne szyfrowanie dysku (LUKS2, FileVault 2, BitLocker z TPM 2.0) - Secure Boot / Verified Boot aktywny - Firewall hosta aktywny, reguły zarządzane przez MDM - Brak konta administratora dla operatora (zasada least privilege) - Klucz FIDO2 biometryczny wymagany do uwierzytelnienia - Agent MDM/EMM zainstalowany i raportujący

Terminal desktopowy zapewnia większy komfort pracy (pełnowymiarowy ekran, klawiatura fizyczna) i jest preferowany dla operatorów wykonujących intensywne prace biurowe, analityczne lub administracyjne. Jednakże terminal desktopowy niesie większe ryzyko niż Pixel — system operacyjny stacjonarny ma większą powierzchnię ataku, a możliwości atestacji sprzętowej są bardziej ograniczone (TPM 2.0 nie oferuje takiego poziomu kontroli jak Titan M2).

Dla tieru STATE terminal desktopowy musi być dedykowany wyłącznie do pracy w SYLION — niedopuszczalny jest dual-use (praca osobista + SYLION na tym samym urządzeniu). Dla tierów STANDARD i PRO dual-use jest dopuszczalny pod warunkiem aktywnego profilu MDM i separacji na poziomie kont użytkownika systemu operacyjnego.

32.4. Polityki MDM/EMM

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 32.2, 32.3, 32.14, 44.1

System zarządzania urządzeniami mobilnymi (MDM — Mobile Device Management) lub w wersji rozszerzonej EMM (Enterprise Mobility Management) jest obowiązkowym komponentem warstwy terminalowej SYLION. MDM odpowiada za: (a) wdrożenie profilu roboczego na terminalu, (b) dystrybucję konfiguracji i polityk bezpieczeństwa, (c) monitorowanie zgodności terminala z baseline, (d) zdalne wymazanie (remote wipe) w przypadku kompromitacji lub utraty, (e) raportowanie stanu urządzenia do warstwy G2.

Wymagania dla systemu MDM w SYLION: - Wsparcie Android Work Profile (profil zarządzany na urządzeniu osobistym — BYOD lub COPE) - Wsparcie macOS MDM (profil konfiguracji + DEP enrollment) - Wsparcie Windows Autopilot / Intune lub równoważne - Wsparcie Linux — agent raportujący (minimalny zakres: szyfrowanie, firewall, wersja OS) - API do integracji z G2 — raport compliance musi być dostępny w czasie rzeczywistym - Szyfrowanie kanału komunikacji MDM ↔ terminal (TLS 1.3, certificate pinning)

Polityki MDM wdrażane na terminalu obejmują: 1. Wymuszenie szyfrowania — terminal bez pełnego szyfrowania nie może być zarejestrowany 2. Wymuszenie blokady ekranu — PIN 6-cyfrowy lub biometria, timeout max. 2 minuty 3. Wymuszenie aktualizacji — krytyczne patche w ciągu 72h, pozostałe w ciągu 14 dni 4. Lista dozwolonych aplikacji — whitelist na profilu roboczym (32.6) 5. Blokada USB/debug/dev — patrz 32.9 6. Geofencing — opcjonalny, dla tieru STATE 7. Wymuszenie VPN — always-on VPN przez profil robocze (IPsec IKEv2)

W przypadku tieru STATE system MDM musi działać on-premise lub w dedykowanej instancji chmurowej operatora — niedopuszczalne jest korzystanie z publicznej instancji SaaS MDM. Dla tierów STANDARD i PRO dopuszczalny jest MDM SaaS pod warunkiem szyfrowania E2E profilu i lokalizacji danych w EOG (Europejski Obszar Gospodarczy).

Uzasadnienie duress PIN mimo modelu zero-data-at-rest. Terminal SYLION nie przechowuje danych operacyjnych (dokumentów, historii, kluczy workloadów). Duress PIN jest jednak wartościowy, ponieważ niszczy: (1) materiał kryptograficzny IPsec (uniemożliwia ponowne zestawienie tunelu bez re-enrollment), (2) profile eSIM (utrudnia identyfikację operatora telekomunikacyjnego), (3) tokeny sesji i cache uwierzytelniania (nawet jeśli krótkotrwałe), (4) profil MDM (uniemożliwia forensic extraction konfiguracji organizacyjnej). Dodatkowo: duress PIN wyświetla "Wrong PIN" bez żadnej wskazówki, że dane zostały zniszczone — przeciwnik nie wie, że operator aktywował procedurę awaryjną.

Rekomendowane rozwiązania MDM: (a) dla Android — Android Enterprise z dowolnym EMM partnerem (np. Ivanti, VMware Workspace ONE, Microsoft Intune), (b) dla macOS/iOS — Jamf Pro lub Mosyle, (c) multiplatformowe — Microsoft Intune, Ivanti Neurons. Wybór konkretnego produktu jest decyzją operatora, pod warunkiem spełnienia wymagań API i compliance.

32.5. Profile robocze (Work Profiles)

Status: [N] Normatywny Odbiorca: Administrator, Operator Wpływ na baseline: Wysoki Powiązane rozdziały: 32.2, 32.4, 32.6

Profil roboczy (Work Profile) stanowi fundamentalny mechanizm separacji środowiska SYLION od danych osobistych operatora na terminalu mobilnym. Na platformie Android profil roboczy jest realizowany przez Android Work Profile API — odrębną przestrzeń użytkownika z własnym kluczem szyfrującym, oddzielnym magazynem aplikacji i danych oraz izolowanym schowkiem systemowym.

W kontekście SYLION profil roboczy zawiera wyłącznie: - Klient VPN — konfiguracja IPsec IKEv2 do routera/bezpośrednio do G1 - Klient sesji — aplikacja renderująca strumień pikseli z Session Broker - Aplikacja uwierzytelniająca — obsługa FIDO2, tokeny OIDC - Agent MDM — raportowanie compliance - Opcjonalnie: Klient Matrix (jeśli dopuszczony przez politykę jako native app)

Żadne inne aplikacje nie są dozwolone w profilu roboczym bez jawnej zgody administratora. Operator nie ma uprawnień do instalacji dodatkowych aplikacji w profilu roboczym — wszelkie zmiany wymagają aktualizacji polityki whitelist (32.6).

Kluczowe właściwości profilu roboczego: - Izolacja danych: dane profilu roboczego nie są dostępne z profilu osobistego i odwrotnie - Izolacja schowka: kopiuj/wklej między profilami jest zablokowane przez politykę MDM - Izolacja powiadomień: powiadomienia z profilu roboczego są oznaczone ikoną walizki (briefcase icon) i nie ujawniają treści na ekranie blokady - Niezależne szyfrowanie: profil roboczy jest szyfrowany odrębnym kluczem, pochodną PIN/hasła profilu - Możliwość selektywnego wymazania: administrator może wymazać wyłącznie profil roboczy, nie naruszając danych osobistych operatora

Na terminalu desktopowym odpowiednikiem profilu roboczego jest: (a) dedykowane konto użytkownika systemu operacyjnego z ograniczonymi uprawnieniami (Linux/macOS/Windows), (b) kontener aplikacji (np. Flatpak sandbox na Linuksie), (c) w przypadku tieru STATE — dedykowana maszyna (bez dual-use).

Profil roboczy musi być aktywowany przed pierwszym połączeniem z SYLION. Proces aktywacji obejmuje: (1) rejestrację terminala w MDM, (2) wdrożenie profilu roboczego, (3) instalację wymaganych aplikacji z whitelist, (4) sparowanie klucza FIDO2, (5) konfigurację klienta VPN, (6) test połączenia z G1/G2. Cały proces powinien trwać nie dłużej niż 30 minut przy dostępnej dokumentacji.

32.6. App whitelisting

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 32.4, 32.5, 49.1

Whitelist aplikacji (lista dozwolonych aplikacji) jest mechanizmem kontroli oprogramowania zainstalowanego na profilu roboczym terminala. W architekturze SYLION obowiązuje zasada default-deny — wszelkie aplikacje nie znajdujące się na białej liście są automatycznie blokowane przez profil MDM.

Lista bazowa aplikacji dozwolonych na profilu roboczym (Android): | Aplikacja | Package ID (przykład) | Funkcja | |—|—| | Klient VPN SYLION | com.sylion.vpn | Tunel IPsec IKEv2 | | Klient sesji SYLION | com.sylion.session | Renderowanie strumienia pikseli | | Aplikacja FIDO2 | com.sylion.auth | Uwierzytelnienie, tokeny | | Agent MDM | (zależy od dostawcy) | Zarządzanie urządzeniem | | Element (Matrix) | im.vector.app | Komunikacja — opcjonalnie |

Rozszerzenie whitelist wymaga procesu zatwierdzenia: 1. Administrator składa wniosek o dodanie aplikacji z uzasadnieniem biznesowym 2. Zespół bezpieczeństwa przeprowadza ocenę ryzyka (analiza uprawnień, sieć, dane) 3. Aplikacja jest testowana na terminalu referencyjnym w środowisku sandbox 4. Po zatwierdzeniu aplikacja jest dodawana do polityki MDM i dystrybuowana

Na terminalu desktopowym whitelist jest realizowany przez: (a) AppLocker / WDAC na Windows, (b) Santa na macOS, (c) fapolicyd lub AppArmor na Linuksie. Dla terminali desktopowych lista dozwolonych obejmuje także system operacyjny i jego komponenty — podejście to wymaga precyzyjnej konfiguracji, aby nie zablokować aktualizacji systemowych.

Aktualizacja whitelist jest procesem zarządzania zmianą (change management) — każda modyfikacja jest logowana, podlega audytowi i wymaga autoryzacji uprawnionego administratora. W tierze STATE modyfikacja whitelist wymaga dual authorization (zasada czterech oczu — 46.10).

32.7. Szyfrowanie urządzenia (Device Encryption)

Status: [N] Normatywny Odbiorca: Administrator, Operator Wpływ na baseline: Krytyczny Powiązane rozdziały: 32.2, 32.3, 47.1

Pełne szyfrowanie pamięci masowej terminala jest bezwzględnym wymogiem dla wszystkich tierów SYLION. Terminal bez aktywnego szyfrowania nie może być zarejestrowany w systemie MDM i nie zostanie dopuszczony do sesji przez G2.

Wymagania szyfrowania per platforma: - Android (Pixel): File-Based Encryption (FBE) z kluczami chronionymi przez Titan M2. FBE jest domyślnie aktywne na Pixel 8+ i nie może być wyłączone. Weryfikacja: adb shell getprop ro.crypto.state → encrypted - Linux: LUKS2 z AES-256-XTS, klucz chroniony przez TPM 2.0 (jeśli dostępny) lub hasło o entropii min. 80 bitów. Partycja /home musi być szyfrowana; rekomendowane jest szyfrowanie pełnego dysku (FDE) - macOS: FileVault 2 (AES-256-XTS), klucz recovery przechowywany w escrow MDM. SIP (System Integrity Protection) musi być aktywny - Windows: BitLocker z AES-256-XTS, TPM 2.0 wymagany, PIN pre-boot rekomendowany dla STATE. Klucz recovery przechowywany w escrow MDM lub Active Directory

W żadnym przypadku klucz szyfrujący nie jest przechowywany w postaci jawnej poza Secure Element / TPM. Administrator musi mieć dostęp do klucza recovery (escrow) na wypadek awarii terminala — procedura odzyskania jest opisana w 44.15 (Emergency Re-enrollment).

Audyt szyfrowania: system MDM musi raportować status szyfrowania każdego terminala co najmniej raz na 24 godziny. Raport jest przekazywany do G2 jako element device posture (36.5). Zmiana statusu szyfrowania (np. wyłączenie BitLocker) powoduje natychmiastową blokadę dostępu do sesji i alert w SIEM.

32.8. Polityki ekranu blokady (Lock Screen Policies)

Status: [N] Normatywny Odbiorca: Administrator, Operator Wpływ na baseline: Wysoki Powiązane rozdziały: 32.4, 32.7, 44.11

Ekran blokady jest pierwszą barierą fizycznego dostępu do terminala. Polityki ekranu blokady muszą być wdrożone przez MDM i nie mogą być modyfikowane przez operatora.

Wymagania: - Metoda odblokowania: PIN 6-cyfrowy (minimum) lub hasło alfanumeryczne 8+ znaków. Biometria (odcisk palca, rozpoznawanie twarzy) dopuszczona jako metoda wygodna, ale PIN/hasło musi być zawsze dostępne jako fallback - Timeout automatycznej blokady: maksymalnie 2 minuty bezczynności (STANDARD/PRO), maksymalnie 1 minuta (STATE) - Próby odblokowania: po 5 nieudanych próbach — wymuszony cooldown 30 sekund; po 10 nieudanych próbach — wymuszony cooldown 5 minut; po 20 nieudanych próbach — opcja remote wipe (STATE) lub reset profilu roboczego (STANDARD/PRO) - Powiadomienia na ekranie blokady: dla profilu roboczego — wyłącznie ikona powiadomienia bez treści (hide sensitive content) - Kamera na ekranie blokady: wyłączona przez politykę MDM (zapobieganie zdjęciom ekranu z danymi) - Smart Lock / Trust Agents: wyłączone — terminal musi wymagać odblokowania przy każdym użyciu

Na terminalu desktopowym odpowiednikiem jest screensaver z hasłem lub systemowa blokada sesji. Timeout: 5 minut (STANDARD/PRO), 2 minuty (STATE). Po powrocie wymagane jest pełne uwierzytelnienie (hasło + ewentualnie FIDO2 dla STATE).

32.9. Kontrola USB, trybu debugowania i trybu deweloperskiego

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 32.4, 42.1, 46.10

Porty USB, tryb debugowania (ADB) i tryb deweloperski (Developer Options) stanowią poważne wektory ataku na terminal. W architekturze SYLION muszą być zablokowane lub ściśle kontrolowane.

Android (Pixel): - USB debugging (ADB): wyłączony przez politykę MDM (DISALLOW_DEBUGGING_FEATURES). Nie może być włączony przez operatora - Developer Options: ukryte i zablokowane przez politykę MDM - USB file transfer (MTP/PTP): wyłączony na profilu roboczym. Transfer plików do/z SYLION odbywa się wyłącznie przez pipeline CDR (Rozdział 42) - USB accessory mode: zablokowany (zapobieganie atakom BadUSB / USB Rubber Ducky) - OTG (On-The-Go): dozwolony wyłącznie dla klucza FIDO2 USB; inne urządzenia OTG blokowane - Wireless debugging: wyłączony

Desktop/Laptop: - USB mass storage: blokada na poziomie polityki OS (udev rules na Linuksie, GPO na Windows, Profilach konfiguracji macOS). Wyjątek: klucz FIDO2 i autoryzowane klawiatury/myszy - USB DMA attacks: ochrona przez IOMMU (Intel VT-d / AMD-Vi) — włączona w BIOS/UEFI - Thunderbolt/USB4 DMA: blokada nieautoryzowanych urządzeń (Thunderbolt Security Level: User Authorization lub wyższy) - Boot from USB: wyłączony w UEFI, chroniony hasłem UEFI

Wyjątki od blokady USB wymagają formalnego procesu change management z uzasadnieniem biznesowym i zgodą zespołu bezpieczeństwa. Wyjątek jest czasowy (maksymalnie 24 godziny) i logowany w audyt trail. Dla tieru STATE wyjątki USB są niedopuszczalne — jedyny dozwolony USB to klucz FIDO2.

32.10. Funkcje duress i przymusu (Duress and Coercion Functions)

Status: [R] Rekomendowany Odbiorca: Operator, Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 32.11, 44.15, 50.1

Funkcje duress (przymusu) pozwalają operatorowi zasygnalizować sytuację zagrożenia — np. wymuszenie odblokowania terminala pod groźbą fizyczną — w sposób niedetekowalny dla napastnika.

SYLION definiuje następujące mechanizmy duress:

Duress PIN / Hasło awaryjne: Operator posiada alternatywny PIN/hasło, którego użycie powoduje: (a) odblokowanie terminala z ograniczonym widokiem (dummy workspace lub pusty profil), (b) wysłanie cichego alertu do centrum operacyjnego (SOC) z lokalizacją GPS (jeśli dostępna) i znacznikiem czasowym, (c) zainicjowanie procedury wymazania profilu roboczego po opóźnieniu (konfigurowalnym: 5–60 minut), (d) wyłączenie dostępu do sesji SYLION (Session Broker odmawia połączenia dla tokena duress).

Duress gesture (terminal mobilny): Alternatywny gest odblokowania (np. inny palec na czytniku biometrycznym) powiązany z tymi samymi akcjami co Duress PIN.

Panic button (fizyczny): Dla operatorów wysokiego ryzyka (tier STATE, operacje terenowe) — fizyczny przycisk (np. na kluczu FIDO2 lub dedykowanym urządzeniu) wysyłający alert przez niezależny kanał (SMS, satellite beacon).

Silent wipe trigger: Jeśli terminal nie połączy się z systemem MDM przez zdefiniowany okres (konfigurowalny: 24–168 godzin), profil roboczy jest automatycznie wyczyszczany. Funkcja ta chroni przed scenariuszem konfiskaty terminala i przetrzymywania go offline.

Wszystkie funkcje duress są opcjonalne w tierze STANDARD, rekomendowane w PRO i wymagane w STATE. Konfiguracja funkcji duress wymaga indywidualnego szkolenia operatora — niezrozumienie mechanizmu grozi przypadkowym wywołaniem.

32.11. Re-autentykacja sesji i hardware heartbeat

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 32.10, 37.8, 36.4

Sesja operatora w SYLION nie jest bezterminowa. Mechanizm re-autentykacji wymusza okresowe potwierdzenie tożsamości operatora podczas aktywnej sesji, a hardware heartbeat weryfikuje ciągłość i integralność terminala.

Re-autentykacja sesji: - Interwał podstawowy: co 8 godzin (STANDARD), co 4 godziny (PRO), co 2 godziny (STATE) - Re-autentykacja przy eskalacji: zmiana kontekstu bezpieczeństwa (np. dostęp do nowego workloadu, operacja eksportu) wymaga natychmiastowej re-autentykacji FIDO2 - Re-autentykacja po bezczynności: po 15 minutach bezczynności sesja wymaga ponownego uwierzytelnienia (FIDO2 lub PIN). Po 30 minutach sesja jest automatycznie zamykana - Metoda: dotknięcie klucza FIDO2 (biometryczne potwierdzenie) — nie wystarczy sam PIN

Hardware heartbeat: Terminal wysłał okresowy sygnał do G2, potwierdzający: - Obecność i integralność agenta MDM - Status szyfrowania urządzenia - Wersję systemu operacyjnego i klienta SYLION - Hash konfiguracji klienta VPN - Obecność klucza FIDO2 (USB: fizyczna obecność; NFC/BLE: ostatni kontakt)

Interwał heartbeat: co 60 sekund. Brak trzech kolejnych heartbeatów powoduje zawieszenie sesji. Brak heartbeat przez 5 minut powoduje zamknięcie sesji i wymaganie pełnej re-autentykacji.

Hardware heartbeat jest krytyczny dla wykrywania scenariuszy: (a) terminal został fizycznie odłączony od sieci, (b) agent MDM został usunięty lub skompromitowany, (c) szyfrowanie zostało wyłączone, (d) klient SYLION został zastąpiony przez zmodyfikowaną wersję. W każdym z tych scenariuszy sesja jest natychmiast terminowana.

32.12. Remote wipe i unieważnienie (Remote Wipe and Revoke)

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 32.4, 32.10, 44.15

Remote wipe (zdalne wymazanie) jest ostatecznym mechanizmem ochrony danych w przypadku utraty, kradzieży lub kompromitacji terminala. W architekturze SYLION remote wipe działa na dwóch poziomach:

Poziom 1 — Wymazanie profilu roboczego (selective wipe): Usunięcie wyłącznie profilu roboczego SYLION z terminala. Dane osobiste operatora pozostają nienaruszone. Jest to domyślna akcja dla scenariuszy: utrata terminala, odejście operatora z organizacji, zmiana terminala.

Poziom 2 — Pełne wymazanie urządzenia (full wipe): Factory reset całego terminala. Stosowane w scenariuszach: potwierdzony kompromis terminala, konfiskata przez stronę nieprzyjazzną, wymóg regulacyjny (np. RODO — prawo do usunięcia danych).

Procedura remote wipe: 1. Administrator inicjuje żądanie wipe w konsoli MDM 2. Dla full wipe (Poziom 2) — wymagana dual authorization (dwie niezależne osoby uprawnione) 3. Polecenie wipe jest przesyłane do terminala przez kanał MDM 4. Terminal potwierdza wykonanie (jeśli online) lub wykonuje wipe przy następnym połączeniu 5. Zdarzenie jest logowane w SIEM z pełnym audyt trail

Unieważnienie (Revoke): Niezależnie od remote wipe, administrator może natychmiast unieważnić wszystkie tokeny i certyfikaty przypisane do terminala: - Unieważnienie certyfikatu klienta VPN (IPsec) - Unieważnienie tokenów sesji w Session Broker - Unieważnienie rejestracji FIDO2 przypisanej do terminala - Dodanie Device ID do listy blokowanych na G2

Unieważnienie jest natychmiastowe (propagacja < 30 sekund) i nie wymaga połączenia terminala z siecią — terminowanie odbywa się po stronie serwerowej. Nawet jeśli napastnik posiada terminal z ważnym kluczem szyfrującym, nie jest w stanie ustanowić sesji, ponieważ infrastruktura SYLION odmówi połączenia.

Dla tieru STATE unieważnienie jest procedurą automatyczną — trigger: brak heartbeat przez 24h, alert duress, lub raport o kompromisie. Dla tierów STANDARD/PRO unieważnienie jest manualne, ale musi być wykonane w ciągu 4 godzin od zgłoszenia incydentu.

32.13. Inwentaryzacja zasobów (Asset Inventory)

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Średni Powiązane rozdziały: 32.4, 32.14, 46.12

Każdy terminal podłączony do ekosystemu SYLION musi być zarejestrowany w centralnym rejestrze zasobów (Asset Inventory). Rejestr stanowi źródło prawdy (source of truth) o wszystkich urządzeniach końcowych i jest niezbędny do: (a) weryfikacji compliance baseline, (b) planowania aktualizacji, (c) reagowania na incydenty, (d) audytu bezpieczeństwa.

Rejestr zasobów zawiera dla każdego terminala: | Pole | Opis | Źródło | |—|—| | Asset ID | Unikalny identyfikator w systemie SYLION | Generowany przy rejestracji | | Device ID | Identyfikator sprzętowy (IMEI, numer seryjny) | MDM | | Model / Typ | Np. Pixel 8 Pro, ThinkPad X1 Carbon G12 | MDM | | System operacyjny | Wersja OS + build number | MDM | | Status szyfrowania | Aktywne / Nieaktywne | MDM heartbeat | | Status MDM | Enrolled / Compliant / Non-compliant / Wiped | MDM | | Operator przypisany | ID operatora | IAM | | Data rejestracji | Timestamp pierwszej rejestracji | System | | Data ostatniego heartbeat | Timestamp ostatniego sygnału | G2 | | Certyfikaty | Lista certyfikatów i daty ważności | PKI | | Klucze FIDO2 | Identyfikatory sparowanych kluczy | IAM | | Tier | STANDARD / PRO / STATE | Konfiguracja operatora |

Rejestr musi być aktualizowany automatycznie przez integrację MDM → Asset Inventory. Manualne wpisy są dopuszczalne wyłącznie w trybie awaryjnym i muszą być zwalidowane w ciągu 24 godzin.

Przegląd rejestru zasobów (asset review) musi być przeprowadzany co 90 dni (STANDARD/PRO) lub co 30 dni (STATE). Przegląd obejmuje: identyfikację nieaktywnych terminali (brak heartbeat > 30 dni), weryfikację przypisać operator ↔ terminal, sprawdzenie statusu certyfikatów i kluczy.

Terminale nieaktywne powyżej 90 dni muszą być automatycznie wyrejestrowane — ich certyfikaty unieważnione, a tokeny cofnięte. Ponowna rejestracja wymaga pełnej procedury onboardingu.

32.14. Terminal compliance baseline

Status: [N] Normatywny Odbiorca: Administrator, Architekt, Audytor Wpływ na baseline: Krytyczny Powiązane rozdziały: 32.1–32.13, 36.5, 45.8

Terminal compliance baseline to zbiór minimalnych wymagań, które każdy terminal musi spełniać, aby zostać dopuszczony do sesji SYLION. Baseline jest weryfikowany na dwóch etapach: (a) przy rejestracji terminala w MDM, (b) przy każdym żądaniu sesji — G2 sprawdza raport device posture z MDM.

Tabela compliance baseline:

Wymóg	STANDARD	PRO	STATE
Pełne szyfrowanie dysku	Wymagane	Wymagane	Wymagane
Secure Boot / Verified Boot	Wymagane	Wymagane	Wymagane
Agent MDM aktywny	Wymagane	Wymagane	Wymagane
Blokada ekranu (PIN 6+)	Wymagane	Wymagane	Wymagane
Aktualizacje bezpieczeństwa (<72h)	Rekomendowane	Wymagane	Wymagane
FIDO2 sparowany	Wymagane	Wymagane	Wymagane
USB debug wyłączony	Wymagane	Wymagane	Wymagane
Developer mode wyłączony	Wymagane	Wymagane	Wymagane
Whitelist aplikacji aktywny	Rekomendowane	Wymagane	Wymagane
Geofencing	Nie	Opcjonalne	Wymagane
Dedykowane urządzenie (no dual-use)	Nie	Rekomendowane	Wymagane
Duress PIN skonfigurowany	Nie	Rekomendowane	Wymagane
Hardware heartbeat < 5 min	Wymagane	Wymagane	Wymagane
Certyfikat klienta ważny	Wymagane	Wymagane	Wymagane

Terminal niespełniający któregokolwiek z wymagań oznaczonych jako „Wymagane” dla danego tieru otrzymuje status Non-Compliant i jest automatycznie blokowany na poziomie G2. Operator widzi komunikat wskazujący przyczynę niezgodności i instrukcję naprawczą.

Baseline jest wersjonowany — każda zmiana wymaga procesu change management, publikacji nowej wersji i okresu przejściowego (grace period: 7 dni dla STANDARD/PRO, 3 dni dla STATE). W okresie przejściowym terminal niespełniający nowego wymagania otrzymuje ostrzeżenie, ale nie jest blokowany.

Rozdział 33. Router dostępowy i warstwa dostępu

33.1. Rola routera w architekturze SYLION

Status: [N] Normatywny Odbiorca: Architekt, Administrator, Operator Wpływ na baseline: Krytyczny Powiązane rozdziały: 32.1, 34.1, 35.1

Router dostępowy jest pierwszym elementem infrastruktury sieciowej SYLION po stronie operatora. Pełni rolę dedykowanego urządzenia VPN, które ustanawia tunel IPsec IKEv2 do bramy G1 i zapewnia bezpieczną komunikację między terminalem a infrastrukturą chmurową.

Kluczowe funkcje routera w architekturze SYLION: 1. Terminacja klienta VPN — router utrzymuje tunel IPsec IKEv2 do G1, zwalniając terminal z bezpośredniej obsługi kryptografii tunelowej 2. Kill switch — w przypadku utraty tunelu VPN router blokuje cały ruch internetowy (brak ruchu poza tunelem) 3. Segmentacja lokalna — router izoluje terminal SYLION od innych urządzeń w sieci lokalnej (np. IoT, drukarki, prywatne urządzenia) 4. Filtracja DNS — router wymusza korzystanie z serwerów DNS dostarczonych przez SYLION (przez tunel); lokalne zapytania DNS są blokowane 5. Firewall hosta — router blokuje cały ruch przychodzący z sieci lokalnej i internetu, dopuszczając wyłącznie ruch tunelowy

Procedura emergency patching: strongSwan i komponenty krytyczne. strongSwan jest małym projektem open-source (~5 aktywnych deweloperów) stanowiącym krytyczny element bezpieczeństwa SYLION. Procedura: (1) monitoring CVE strongSwan (NVD + oss-sec mailing list + GitHub advisories) — codziennie; (2) przy CVE Critical (CVSS ≥9.0): emergency patch w ciągu 24h, rebuild WSZYSTKICH G1 z nowym obrazem; (3) przy CVE High (CVSS 7.0–8.9): patch w ciągu 72h; (4) przy CVE Medium: patch w następnym scheduled maintenance window; (5) fallback: jeśli patch niedostępny — tymczasowe mitygacje (firewall rules, configuration hardening) + eskalacja do L3. Analogiczna procedura obowiązuje dla: Keycloak, Matrix Synapse, Podman, Firecracker, Alpine, OpenSearch. Historia: CVE-2023-41913 (strongSwan, RCE) — demonstracja, że 0-day w VPN daemon jest realistycznym wektorem.

Router jest traktowany jako asset bezpieczeństwa (security asset — 33.2), a nie zwykłe urządzenie sieciowe. Kompromitacja routera oznacza potencjalną możliwość przechwycenia lub manipulacji ruchem — dlatego router podlega tym samym rygorom zarządzania co terminal: inwentaryzacja, audyt konfiguracji, aktualizacje firmware, rotacja poświadczeń.

W modelu operacyjnym SYLION router jest dostarczany operatorowi jako część hardware kit (cena referencyjna: 150 €, model referencyjny: GL-iNet Beryl AX / MT-3000). Router jest wstępnie skonfigurowany przez administratora przed wydaniem operatorowi — operator nie konfiguruje routera samodzielnie.

Architektura dopuszcza scenariusze bez dedykowanego routera — terminal mobilny może łączyć się bezpośrednio z G1 przez klienta IPsec wbudowanego w system (Android IKEv2 native client lub strongSwan app). Jednakże scenariusz z routerem jest preferowany, ponieważ zapewnia kill switch na poziomie sieciowym i separację od sieci lokalnej.

33.2. Router jako asset bezpieczeństwa

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 33.1, 32.13, 46.12

Router dostępowy SYLION jest klasyfikowany jako security asset — urządzenie, którego kompromitacja może bezpośrednio wpłynąć na poufność, integralność lub dostępność sesji operatora. Klasyfikacja ta nakłada na router wymagania analogiczne do terminala:

Rejestracja w Asset Inventory — każdy router jest rejestrowany z numerem seryjnym, MAC, wersją firmware, przypisanym operatorem i datą wdrożenia

Audyt konfiguracji — konfiguracja routera jest wersjonowana i porównywana z baseline co 24 godziny (automatyczny check przez system zarządzania)

Monitorowanie integralności — router raportuje swój status (firmware hash, uptime, status tunelu) do warstwy zarządzania (Zone)

Procedury incydentowe — utrata, kradzież lub podejrzenie kompromitacji routera uruchamia procedurę IR (Rozdział 50) obejmującą: unieważnienie certyfikatu routera, powiadomienie operatora, wydanie nowego routera

Router przechowuje materiał kryptograficzny do ustanowienia tunelu IPsec: certyfikat klienta (X.509) i odpowiadający klucz prywatny. Klucz prywatny jest przechowywany w pamięci routera i chroniony szyfrowaniem konfiguracji. Rotacja certyfikatu routera — co 90 dni (STANDARD/PRO), co 30 dni (STATE).

Unieważnienie certyfikatu (CRL / OCSP) musi być sprawdzane przez G1 przy każdym ustanowieniu SA.

Fizyczne zabezpieczenie routera: operator jest odpowiedzialny za fizyczną kontrolę nad routerem. Instrukcja operatora zawiera wytyczne dotyczące: przechowywania routera w zamkniętym pomieszczeniu, identyfikacji oznak manipulacji fizycznej (tamper-evident seals — rekomendowane dla STATE), procedury postępowania w przypadku podejrzenia fizycznego dostępu osób trzecich.

33.3. Wymagania sprzętowe (GL-iNet Beryl AX / MT-3000)

Status: [N] Normatywny Odbiorca: Administrator, Zakupy Wpływ na baseline: Wysoki Powiązane rozdziały: 33.1, 33.4, 49.2

GL-iNet Beryl AX (MT-3000) jest referencyjnym routerem dostępowym SYLION. Wybór tego modelu wynika z: (a) wsparcia OpenWrt jako firmware, (b) wydajności wystarczającej do obsługi tunelu IPsec z AES-256-GCM przy przepustowości > 300 Mbps, (c) kompaktowej formy (podróżny), (d) ceny akceptowalnej w kontekście hardware kit (150 €).

Specyfikacja techniczna modelu referencyjnego: | Parametr | Wartość | |—| | SoC | MediaTek MT7981B (Filogic 820), dual-core ARM Cortex-A53 @ 1.3 GHz | | RAM | 512 MB DDR4 | | Flash | 256 MB NAND | | Wi-Fi | Wi-Fi 6 (802.11ax), 2.4 GHz + 5 GHz, 2x2 MIMO | | Ethernet | 1x WAN (1 Gbps), 1x LAN (1 Gbps) | | USB | 1x USB 3.0 (do podłączenia modemu LTE/5G) | | Zasilanie | USB-C 5V/3A | | Wymiary | 118 x 83 x 30 mm | | Masa | ~215 g | | Firmware bazowy | OpenWrt 23.05+ (hardened — 33.4) | | Crypto acceleration | Tak (sprzętowy AES) |

Wymagania minimalne dla routera alternatywnego (jeśli MT-3000 jest niedostępny): - Wsparcie OpenWrt 23.05+ z pakietem strongSwan - RAM ≥ 256 MB (512 MB rekomendowane) - Sprzętowa akceleracja AES (bez akceleracji przepustowość IPsec spada poniżej akceptowalnego poziomu) - Ethernet WAN + LAN (lub Wi-Fi WAN + Ethernet LAN) - USB do opcjonalnego podłączenia modemu LTE

Alternatywne modele dopuszczone: GL-iNet Flint 2 (GL-MT6000) dla wyższej przepustowości, GL-iNet Slate AX (GL-AXT1800) jako tańsza alternatywa. Każdy alternatywny model musi przejść procedurę walidacji firmware (33.4) przed wdrożeniem.

33.4. Wymagania firmware (OpenWrt hardened)

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 33.3, 33.5, 49.2

Firmware routera dostępowego SYLION bazuje na OpenWrt w wersji hardened — zmodyfikowanej pod kątem bezpieczeństwa i ograniczonej do minimalnego zestawu funkcji wymaganych przez SYLION.

Modyfikacje hardening względem stockowego OpenWrt: 1. Usunięcie zbędnych pakietów: usunięte są wszystkie usługi niewymagane przez SYLION: serwer DHCP na WAN, UPnP, mDNS/Avahi, LuCI (panel webowy — opcjonalnie zachowany w trybie readonly dla diagnostyki), usb-storage (chyba że wymagany do modemu LTE) 2. Minimalne jądro: kernel skompilowany z opcjami hardening: KASLR, stack protector, KASAN (debug builds), read-only kernel text, disabled modules loading (po starcie) 3. strongSwan: zainstalowany z pakietów: strongswan-full, charon-systemd, pki, swanctl. Konfiguracja IPsec IKEv2 — patrz 33.5.4. Firewall: nftables z polityką default-drop na INPUT/FORWARD. Dozwolony wyłącznie: (a) ruch IPsec ESP/IKE z terminala do WAN, (b) ruch DNS/DHCP z terminala do routera, (c) ruch zarządzania (SSH) z autoryzowanego adresu 5. DNS resolver: dnsmasq skonfigurowany do przekierowania wszystkich zapytań DNS przez tunel IPsec do serwerów DNS SYLION. Zapytania DNS do internetu poza tunelem — blokowane 6. SSH: klucz publiczny (Ed25519), hasło wyłączone, port zmieniony (nie 22), rate limiting, dostęp wyłącznie z LAN lub przez tunel zarządzania 7. Logging: rsyslog przekazujący logi przez tunel do systemu SIEM w Zone 5. Lokalny bufor logów: max. 1 MB (rotacja) 8. Podpis firmware: firmware jest podpisywany kluczem Ed25519 w procesie budowy. Router weryfikuje podpis przed aktualizacją (sysupgrade z weryfikacją podpisu) 9. Immutability: partycja rootfs zamontowana read-only. Konfiguracja przechowywana na osobnej partycji overlay (szyfrowanej, jeśli hardware to umożliwia)

Procedura budowy firmware: automatyczny pipeline CI/CD (GitLab CI lub GitHub Actions) z reproducibile builds. Artefakt firmware jest budowany z pinowanych wersji źródeł, a hash SHA-256 jest publikowany w rejestrze artefaktów. Administrator weryfikuje hash przed wgraniem firmware na router.

33.5. Konfiguracja klienta IPsec IKEv2

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 33.4, 34.1, 35.3

Router dostępowy łączy się z bramą G1 przy użyciu protokołu IPsec IKEv2 w implementacji strongSwan. Poniżej przedstawiono referencyjną konfigurację klienta.

Plik /etc/swanctl/swanctl.conf (szablon):

```
connections {
  sylion-g1 {
    version = 2
    local_addrs = %any
    remote_addrs = g1.sylion.example.com
    local {
      auth = pubkey
      certs = router-cert.pem
      id = "C=PL, O=SYLION, CN=router-<ASSET_ID>"
    }
    remote {
      auth = pubkey
      cacerts = sylion-ca.pem
      id = "C=PL, O=SYLION, CN=g1.sylion.example.com"
    }
    children {
      sylion-tunnel {
        local_ts = 0.0.0.0/0
        remote_ts = 10.0.0.0/8
        esp_proposals = aes256gcm128-sha384-ecp384
        life_time = 3600
        rekey_time = 3000
        dpd_action = restart
        start_action = start
        close_action = restart
      }
    }
    proposals = aes256-sha384-ecp384
    rekey_time = 14400
    dpd_delay = 30
    dpd_timeout = 150
  }
}
```

Kluczowe parametry: - Uwierzytelnienie: wzajemne uwierzytelnienie certyfikatami X.509 (pubkey). Certyfikat routera wystawiony przez CA SYLION, certyfikat G1 wystawiony przez tę samą CA - Propozycje IKE: AES-256 + SHA-384 + ECP-384 (NIST P-384). Brak słabszych algorytmów w propozycji - Propozycje ESP: AES-256-GCM-128 + SHA-384 + ECP-384. GCM zapewnia AEAD (szyfrowanie + integralność w jednej operacji) - SA lifetime (Child SA): 3600 sekund (1 godzina), rekey po 3000 sekund. PFS (Perfect Forward Secrecy) wymagany przy każdym rekeying - IKE SA lifetime: 14400 sekund (4 godziny), rekey po 12000 sekund - DPD (Dead Peer

Detection): co 30 sekund, timeout 150 sekund. Po timeout — restart tunelu - Start action: tunel jest nawiązywany automatycznie po starcie routera - Close/DPD action: restart — automatyczna próba ponownego ustanowienia tunelu

Certyfikat routera jest generowany przez administratora w procesie provisioningu (47.3) i instalowany na routerze podczas wstępnej konfiguracji. Klucz prywatny jest generowany na routerze (nigdy nie opuszcza urządzenia, jeśli hardware na to pozwala) lub w bezpiecznym środowisku i transferowany przez kanał szyfrowany.

33.6. Kill switch — implementacja

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 33.1, 33.5, 34.1

Kill switch jest mechanizmem gwarantującym, że żaden ruch sieciowy z terminala nie opuści routera bez ochrony tunelu IPsec. W przypadku awarii tunelu, braku połączenia z G1 lub restartu routera — cały ruch internetowy jest blokowany do momentu ponownego ustanowienia tunelu.

Implementacja kill switch opiera się na regułach nftables:

```
table inet killswitch {
    chain input {
        type filter hook input priority 0; policy drop;
        # Localhost iif lo accept # LAN → router (DHCP, DNS) iifname "br-lan" udp dport { 53, 67 } accept iifname "br-lan" tcp dport 53 accept # SSH z LAN (zarządzanie) iifname "br-lan" tcp dport <MGMT_PORT> accept # IPsec z WAN iifname "wan" udp dport { 500, 4500 } accept iifname "wan" ip protocol esp accept # Established/related ct state established,related accept }
        chain forward {
            type filter hook forward priority 0; policy drop;
            # LAN → tunel IPsec (tylko przez interfejs ipsec0/xfrm) iifname "br-lan" oifname "ipsec0" accept # Tunel IPsec → LAN (odpowiedzi) iifname "ipsec0" oifname "br-lan" ct state established,related accept # BLOCK: LAN → WAN bez tunelu — kill switch iifname "br-lan" oifname "wan" drop }
        chain output {
            type filter hook output priority 0; policy drop;
            # Localhost oif lo accept # Router → WAN: tylko IKE i ESP iifname "wan" udp dport { 500, 4500 } accept oifname "wan" ip protocol esp accept # Router → WAN: DHCP client oifname "wan" udp dport 67 accept # Router → LAN oifname "br-lan" accept # Established ct state established,related accept }
    }
}
```

Kluczowe zasady: - FORWARD: default DROP — żaden ruch z LAN na WAN nie jest dopuszczony bez przejścia przez interfejs tunelu IPsec - OUTPUT: default DROP — router sam nie wysyła ruchu na WAN poza IKE/ESP i DHCP client - Brak bypass: nie istnieje żadna reguła zezwalająca na ruch LAN → WAN poza tunelem

Kill switch musi być aktywny natychmiast po starcie routera — reguły nftables są ładowane z initd przed uruchomieniem strongSwan. Oznacza to, że w okresie między startem routera a ustanowieniem tunelu cały ruch jest blokowany (oczekiwane zachowanie).

Testowanie kill switch: procedura walidacji obejmuje: (a) wyłączenie tunelu → weryfikacja braku ruchu na WAN, (b) restart routera → weryfikacja blokady w okresie boot, (c) symulacja awarii G1 → weryfikacja braku ruchu poza IPsec. Testy przeprowadzane co 90 dni lub po każdej aktualizacji firmware.

33.7. Firewall i filtracja DNS

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 33.4, 33.6, 34.7

Firewall routera (opisany w 33.6) jest uzupełniony o filtrację DNS, która stanowi dodatkową warstwę ochrony przed złośliwymi domenami i wyciekami zapytań DNS.

Architektura DNS na routerze: - Router uruchamia lokalny resolver dnsmasq na porcie 53 (nasłuch wyłącznie na br-lan) - Dnsmasq przekazuje wszystkie zapytania (forwarder) do serwerów DNS SYLION dostępnych wyłącznie przez tunel IPsec (np. 10.x.x.53 i 10.x.x.54) - Zapytania DNS do zewnętrznych serwerów (8.8.8.8, 1.1.1.1 itp.) są blokowane przez firewall (kill switch nie dopuszcza ruchu poza tunelem)

Filtracja DNS po stronie serwera SYLION: Serwery DNS w Zone 4 (usługi wspólne) stosują filtrację: - Blokada znanych domen malware/phishing (listy threat intelligence, aktualizowane co 4h) - Blokada domen C2 (Command & Control) - Opcjonalnie: blokada kategorii (social media, streaming — konfigurowane przez politykę organizacyjną) - Logowanie zapytań DNS per operator (anonimizowane lub z identyfikatorem operatora, zależnie od polityki)

DNS-over-TLS (DoT) wewnątrz tunelu: Rekomendowane (nie wymagane) jest użycie DoT (port 853) do szyfrowania zapytań DNS wewnątrz tunelu IPsec. Dodaje to warstwę ochrony przed potencjalnym nasłuchem wewnątrz Zone 2/4, choć tunel IPsec sam zapewnia szyfrowanie.

DNS leak prevention: Kill switch (33.6) gwarantuje, że zapytania DNS nie mogą opuścić routera poza tunelem. Dodatkowa ochrona: dnsmasq jest skonfigurowany z -no-resolv (brak czytania /etc/resolv.conf) i --server=10.x.x.53 (hardcoded serwery SYLION). Operator nie może zmienić konfiguracji DNS na routerze.

33.8. Segmentacja lokalna

Status: [R] Rekomendowany Odbiorca: Administrator, Operator Wpływ na baseline: Średni Powiązane rozdziały: 33.1, 33.6, 38.1

Segmentacja lokalna oznacza izolację terminala SYLION od innych urządzeń w sieci domowej lub biurowej operatora. Router dostępowy tworzy odrębną podsieć (np. 192.168.10.0/24) na porcie LAN, do której podłączony jest wyłącznie terminal SYLION.

Scenariusz referencyjny:

[Internet] ← WAN → [Router SYLION] ← LAN → [Terminal Pixel/Laptop] ↑ (tunel IPsec → G1)

Router SYLION nie jest podłączony jako klient do sieci domowej operatora — jest podłączony bezpośrednio do łącza ISP (Ethernet WAN) lub do sieci domowej jako upstream WAN (kaskada routerów). W obu przypadkach terminal SYLION jest w izolowanej podsieci za routerem SYLION i nie ma łączności z urządzeniami w sieci domowej (telewizory, IoT, drukarki, komputery osobiste).

Reguły segmentacji (nftables): - Ruch z br-lan dozwolony wyłącznie do interfejsu tunelu (ipsec0) i do routera (DNS/DHCP/SSH) - Ruch z br-lan do br-wan (upstream LAN, jeśli kaskada) — blokowany - Multicast/broadcast z WAN → LAN — blokowany - ARP na LAN — ograniczony do terminala i routera

Dla operatorów, którzy nie mogą podłączyć routera SYLION bezpośrednio do ISP (np. hotel, coworking), router działa w trybie WISP (Wireless ISP) — łączy się z istniejącą siecią Wi-Fi jako klient WAN, a terminal jest w izolowanej podsieci LAN. W tym scenariuszu cała komunikacja terminala z internetem i tak odbywa się przez tunel IPsec, więc segmentacja jest zachowana.

Segmentacja lokalna jest rekomendowana dla wszystkich tierów i wymagana dla STATE.

33.9. Ochrona panelu zarządzania

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 33.4, 33.8, 46.2

Panel zarządzania routerem (SSH i opcjonalnie LuCI) musi być chroniony przed nieautoryzowanym dostępem.

SSH: - Uwierzytelnienie wyłącznie kluczem publicznym Ed25519 — hasło wyłączone (PasswordAuthentication no) - Port SSH zmieniony na niestandardowy (np. 2222 lub inny z zakresu 1024–65535) - Nasłuch wyłącznie na interfejsie br-lan (nie na WAN) - Rate limiting: max. 3 próby połączenia w ciągu 60 sekund z jednego IP (fail2ban lub nftables limit) - Opcjonalnie: SSH dostępny przez tunel zarządzania z Zone 5 (dla zdalnej administracji)

LuCI (panel webowy): - Domyślnie wyłączony w hardened firmware SYLION - Jeśli aktywowany (dla diagnostyki): tryb readonly, HTTPS z self-signed certificate, dostęp wyłącznie z LAN, sesja max. 15 minut, uwierzytelnienie hasłem o entropii min. 80 bitów - Po zakończeniu diagnostyki — wyłączenie LuCI

Klucze administracyjne: Klucz SSH do routera jest generowany w procesie provisioningu i przechowywany w systemie zarządzania sekretami (HashiCorp Vault — 46.5) lub w bezpiecznym repozytorium administratora. Klucz prywatny SSH nigdy nie jest przesyłany mailem ani przechowywany w postaci jawnej na dysku administratora.

Dostęp do panelu zarządzania jest logowany (syslog → SIEM przez tunel). Każda sesja SSH jest rejestrowana z: timestampem, źródłowym IP (LAN), fingerprint klucza SSH, długością sesji.

33.10. Rotacja poświadczeń

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 33.5, 47.6, 47.10

Poświadczenia routera (certyfikaty IPsec, klucze SSH, hasła awaryjne) podlegają obowiązkowej rotacji:

Poświadczenie	Okres ważności	Rotacja	Tier STATE
Certyfikat klienta IPsec (X.509)	180 dni	Co 150 dni (30 dni przed wygaśnięciem)	90 dni / co 60 dni
Klucz prywatny IPsec (ECDSA P-384)	360 dni	Co 330 dni	180 dni / co 150 dni
Klucz SSH administratora	360 dni	Co 330 dni	180 dni / co 150 dni
Hasło awaryjne (recovery)	180 dni	Co 150 dni	90 dni / co 60 dni
PSK (jeśli używany — niezalecany)	N/A	N/A — PSK niedopuszczalny	N/A

Procedura rotacji certyfikatu IPsec: 1. System PKI (Zone 5) generuje nowy certyfikat z 30-dniowym overlap (stary i nowy certyfikat są ważne jednocześnie) 2. Nowy certyfikat jest dostarczany na router przez tunel zarządzania (SCP/SFTP przez IPsec) 3. Konfiguracja strongSwan jest aktualizowana (podmiana pliku certyfikatu, restart charon) 4. Stary certyfikat jest unieważniany po potwierdzeniu działania nowego 5. Zdarzenie jest logowane w audyt trail

Automatyzacja rotacji: rekomendowana jest pełna automatyzacja rotacji certyfikatów przez pipeline Ansible (Zone 5 → router przez tunel zarządzania). W przypadku braku automatyzacji — rotacja manualna z checklistą i dual verification.

33.11. Detekcja naruszenia konfiguracji

Status: [N] Normatywny Odbiorca: Administrator, SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 33.4, 33.9, 50.1

Router dostępowy musi raportować wszelkie zmiany konfiguracji, które mogą świadczyć o kompromitacji lub nieautoryzowanej modyfikacji.

Mechanizmy detekcji: 1. Config hash check: Po starcie i co 60 minut router oblicza SHA-256 hash kluczowych plików konfiguracyjnych: /etc/config/, /etc/swanctl/, /etc/nftables.conf, /etc/dropbear/. Hash jest porównywany z wartością referencyjną przechowywaną w Zone 5. Rozbieżność generuje alert CRITICAL w SIEM 2. Filesystem integrity: Na partycji rootfs (read-only) — sprawdzenie montowania: mount | grep "ro,". Jeśli rootfs nie jest zamontowany read-only — alert CRITICAL 3. Process monitoring: Lista procesów jest porównywana z białą listą (strongSwan, dnsmasq, dropbear, syslogd, cron). Nieznany proces → alert HIGH 4. Network anomaly: Router monitoruje ruch na interfejsie WAN — wykrycie ruchu ESP do adresu innego niż G1, lub ruchu na portach innych niż 500/4500 → alert HIGH 5. Timestamp anomaly: Zegar routera jest synchronizowany przez NTP (przez tunel). Odchylenie > 30 sekund → alert MEDIUM (zegar jest krytyczny dla ważności certyfikatów)

Alerty są przesyłane przez tunel IPsec do SIEM w Zone 5. W przypadku braku tunelu (tunel padł) — alerty są buforowane lokalnie i wysyłane po ponownym ustanowieniu tunelu. Jeśli bufor jest pełny (1 MB) — najstarsze wpisy są nadpisywane.

Reakcja na alerty: playbook IR (50.8) definiuje procedury dla każdego typu alertu routera. Alert CRITICAL wymaga natychmiastowej reakcji (< 15 minut) obejmującej: izolację routera, weryfikację integralności, w razie potrzeby — wymianę routera i unieważnienie poświadczeń.

33.12. Testy integralności tunelu

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Średni Powiązane rozdziały: 33.5, 33.6, 34.1

Testy integralności tunelu IPsec weryfikują poprawność działania tunelu, kill switch i parametrów kryptograficznych. Testy dzielą się na automatyczne (periodyczne) i manualne (na żądanie).

Testy automatyczne (co 24 godziny): 1. Tunnel status check: swanctl --list-sas → weryfikacja: SA jest w stanie ESTABLISHED, algorytm zgodny z polityką (aes256gcm128-sha384-ecp384), PFS aktywny 2. Latency test: ping do G1 inner IP przez tunel → próg alertu: RTT > 200 ms (ciągły), pakiet loss > 2% 3. Kill switch test: próba połączenia TCP na port 80 do publicznego IP (np. 1.1.1.1) z adresu LAN → oczekiwany wynik: connection refused/timeout (kill switch blokuje) 4. DNS leak test: zapytanie DNS do publicznego resolvera (np. 8.8.8.8 port 53) z adresu LAN → oczekiwany wynik: timeout (blokowane przez kill switch) 5. Rekey test: weryfikacja, że SA rekey nastąpił w ciągu ostatnich rekey_time sekund → brak rekey świadczy o problemie

Testy manualne (procedura walidacji): 1. Rozłączenie tunelu → weryfikacja braku łączności terminala z internetem 2. Restart routera → pomiar czasu do ponownego ustanowienia tunelu (akceptowalny: < 30 sekund) 3. Symulacja awarii G1 → weryfikacja automatycznego przełączenia na backup G1 (jeśli skonfigurowany) 4. Zmiana klucza → weryfikacja odrzucenia przez G1 przy starej konfiguracji

Wyniki testów automatycznych są raportowane do SIEM. Wyniki testów manualnych są dokumentowane w protokole walidacji i przechowywane w rejestrze artefaktów.

33.13. Routery referencyjne

Status: [R] Rekomendowany Odbiorca: Administrator, Zakupy Wpływ na baseline: Niski Powiązane rozdziały: 33.3, 33.4

Poza modelem referencyjnym GL-iNet MT-3000 (33.3), dopuszczone są następujące routery, pod warunkiem spełnienia wymagań firmware (33.4):

Model	SoC	RAM	Uwagi	Cena ok.
GL-iNet MT-3000 (Beryl AX)	MT7981B	512 MB	Referencyjny, podróżny	150 €
GL-iNet GL-MT6000 (Flint 2)	MT7986A	1 GB	Wydajność biurkowa, 2.5G WAN	200 €
GL-iNet GL-AXT1800 (Slate AX)	IPQ6000	512 MB	Alternatywa budżetowa	120 €
PC Engines APU4	AMD GX-412TC	4 GB	Brak Wi-Fi, najwyższa kontrola, idealne dla STATE	250 €
Protectli Vault FW4B	Intel Celeron J3160	4–8 GB	Mini-PC z wieloma portami, idealne dla STATE	350 €

Dla tieru STATE rekomendowane są routery klasy mini-PC (APU4, Protectli) zapewniające: (a) większą wydajność kryptograficzną, (b) możliwość uruchomienia dodatkowych warstw monitoringu, (c) lepsze możliwości audytu (większa pamięć flash, pełne logi).

Każdy router spoza listy referencyjnej wymaga indywidualnej walidacji obejmującej: (a) budowę hardened firmware, (b) testy wydajności IPsec, (c) testy kill switch, (d) testy stabilności (72h continuous uptime). Walidacja jest dokumentowana i archiwizowana.

33.14. Cykl życia routera

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Średni Powiązane rozdziały: 33.2, 33.10, 49.2

Cykl życia routera obejmuje fazy: provisioning → deployment → operation → maintenance → decommission.

Provisioning (przygotowanie): 1. Zakup routera z listy referencyjnej (33.13) 2. Flash hardened firmware SYLION (33.4) 3. Generowanie certyfikatu IPsec i instalacja na routerze (33.5, 47.3) 4. Instalacja klucza SSH administratora (33.9) 5. Konfiguracja kill switch, firewalla, DNS (33.6, 33.7) 6. Test walidacyjny: tunel, kill switch, DNS leak (33.12) 7. Rejestracja w Asset Inventory (33.2) 8. Oznaczenie tamper-evident seal (STATE) 9. Przekazanie operatorowi z dokumentacją

Deployment (wdrożenie): Operator podłącza router do łącza internetowego (Ethernet WAN lub Wi-Fi WISP). Router automatycznie ustanawia tunel IPsec do G1. Operator podłącza terminal do portu LAN (Ethernet) lub sieci Wi-Fi routera.

Operation (eksploatacja): Router działa autonomicznie. Monitorowanie: heartbeat, config hash, testy integralności. Aktualizacje firmware: przez pipeline OTA (Rozdział 49).

Maintenance (obsługa): Rotacja certyfikatów (33.10), aktualizacje firmware (49.2), wymiana w razie awarii.

Decommission (wycofanie): 1. Unieważnienie certyfikatu routera (CRL) 2. Usunięcie z Asset Inventory 3. Factory reset routera (full erase) 4. Fizyczne zniszczenie flash (STATE) lub bezpieczne wymazanie (STANDARD/PRO) 5. Dokumentacja w audyt trail

Maksymalny okres eksploatacji routera: 5 lat od daty produkcji (ograniczony wsparciem firmware i komponentów). Po tym okresie — obowiązkowa wymiana.

33.15. Moduły autonomiczne routera [A]

Status: [A] Autonomiczny Odbiorca: Architekt, Administrator (zaawansowany) Wpływ na baseline: Niski (niezależne od baseline) Powiązane rozdziały: 33.1, 34.9, 34.11

Moduły autonomiczne to rozszerzenia routera wykraczające poza standardowy baseline SYLION. Są przeznaczone dla zaawansowanych scenariuszy operacyjnych i nie są objęte standardowym wsparciem.

[A] Moduł IMEI/IMSI monitoring: Router z podłączonym modemem LTE monitoruje IMEI i IMSI SIM oraz parametry sieci komórkowej (Cell ID, LAC, RSSI, SINR). Anomalie (zmiana Cell ID w lokalizacji stacjonarnej, nieoczekiwana zmiana IMSI, nagły spadek RSSI z jednoczesnym wzrostem nieznanego sygnału) mogą wskazywać na atak IMSI catcher / fałszywą stację bazową (rogue BTS).

Moduł raportuje anomalie do SIEM. Operator jest powiadamiany komunikatem: „Wykryto anomalie sieci komórkowej — zalecana zmiana lokalizacji lub przejście na łącze kablowe.”

[A] Moduł Starlink: Router obsługuje Starlink jako upstream WAN. Specyfika: (a) wysoka latencja (40–100 ms typowa, okazjonalnie > 200 ms), (b) zmienne IP (CGNAT), (c) potencjalne ograniczenia IPsec ESP w niektórych regionach. Moduł obejmuje konfigurację NAT-T (34.4), monitorowanie jakości łącza i automatyczne przełączanie na LTE backup.

[A] Moduł BTS forcing detection: Zaawansowany moduł wykrywania wymuszenia połączenia z konkretną stacją bazową (BTS forcing / cell lock attack). Wymaga modemu LTE z obsługą AT commands do odczytu parametrów sieci. Moduł porównuje obserwowane stacje bazowe z bazą znanych BTS (OpenCellID lub lokalną bazą) i raportuje anomalie.

[A] Moduł multi-WAN failover: Router z wieloma interfejsami WAN (Ethernet + LTE + Wi-Fi WISP) i automatycznym przełączaniem. Priorytet: Ethernet → Wi-Fi → LTE. Przełączenie jest transparentne dla tunelu IPsec (MOBIKE — RFC 4555).

Moduły autonomiczne wymagają dedykowanego firmware z dodatkowymi pakietami. Wdrożenie wymaga zaawansowanej wiedzy sieciowej i jest przeprowadzane przez certyfikowanego administratora.

Rozdział 34. Warstwa transportowa i łączność

34.1. IPsec IKEv2 jako standard transportowy

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 33.5, 35.3, 47.3

IPsec IKEv2 (Internet Key Exchange version 2, RFC 7296) w implementacji strongSwan jest jedynym dopuszczonym protokołem tunelowym w architekturze SYLION. Wybór ten jest świadomy i nieprzypadkowy:

Dlaczego IPsec IKEv2, a nie WireGuard: 1. Dojrzałość standardu: IPsec jest standardem IETF z ponad 20-letnią historią, wielokrotnie audytowanym i certyfikowanym (FIPS 140-3, Common Criteria). WireGuard nie posiada certyfikacji FIPS 2. Elastyczność kryptograficzna: IKEv2 pozwala na negocjację algorytmów i ich wymianę bez

zmiany protokołu. WireGuard jest zablokowany na Curve25519/ChaCha20 — brak możliwości przejścia na algorytmy PQC bez zmiany protokołu 3. Certyfikaty X.509: IKEv2 natywnie wspiera uwierzytelnienie certyfikatami X.509 — kluczowe dla PKI SYLION (Rozdział 47). WireGuard używa wyłącznie kluczy statycznych 4. MOBIKE: IKEv2 obsługuje MOBIKE (RFC 4555) — bezstratne przełączanie interfejsów sieciowych (np. Wi-Fi → LTE) bez restartowania tunelu. WireGuard obsługuje roaming, ale z innymi ograniczeniami 5. Wsparcie NAT-T: Natywna enkapsulacja UDP port 4500 (RFC 3947) — kluczowe dla CGNAT 6. strongSwan: Implementacja o najwyższej jakości, aktywnie rozwijana, z wsparciem FIPS (plugin openssl-fips) 7. Obowiązek regulacyjny: Wiele regulacji (NATO, EU restricted) wymaga IPsec jako standard transportowy

Dlaczego nie TLS VPN (OpenVPN, SSL VPN): IPsec działa na warstwie 3 (sieciowej), zapewniając transparentną ochronę wszystkich protokołów. TLS VPN działa na warstwie 4/7 i wymaga proxy lub wrapper — mniejsza wydajność, większa powierzchnia ataku.

strongSwan w SYLION jest kompilowany z następującymi pluginami: aes, gcm, sha2, hmac, ecp, x509, pem, pkcs1, pkcs8, revocation, constraints, pubkey, openssl (z FIPS provider dla STATE), kernel-netlink, socket-default, vici, updown.

34.2. Profile kryptograficzne

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 34.1, 34.3, 47.1

Profile kryptograficzne definiują dopuszczalne algorytmy dla tunelu IPsec IKEv2 w SYLION.

Profil bazowy (STANDARD / PRO): | Parametr | Wartość | |—| | IKE Encryption | AES-256-GCM-16 (128-bit ICV) | | IKE Integrity | SHA-384 (implicit w GCM, explicit dla non-AEAD fallback) | | IKE DH Group | ECP-384 (NIST P-384, Group 20) | | IKE PRF | SHA-384 | | ESP Encryption | AES-256-GCM-16 (128-bit ICV) | | ESP Integrity | (zintegrowana w GCM) | | ESP DH (PFS) | ECP-384 (NIST P-384, Group 20) |

Profil STATE: Profil STATE rozszerza profil bazowy o: - Wyłączne użycie FIPS 140-3 validated cryptographic module (strongSwan z OpenSSL FIPS provider) - Opcjonalnie: PQC hybrid — IKEv2 z ML-KEM-768 jako dodatkowy key agreement (draft-ietf-ipsecme-ikev2-pqc) - Dozwolony fallback: AES-256-CBC + SHA-384 + ECP-384 (jeśli GCM jest niedostępny na jednym z endpointów — scenariusz interoperacyjności)

Algorytmy zakazane: - DES, 3DES, RC4, Blowfish — przestarzałe, niedopuszczalne - AES-128 — zbyt krótki klucz dla klasyfikacji STATE - SHA-1 — kolizje znane od 2017, niedopuszczalny - DH Group 1, 2, 5 (MODP 768, 1024, 1536) — zbyt krótkie - DH Group 14 (MODP 2048) — dopuszczalny wyłącznie jako fallback w STANDARD, niezalecany - RSA < 3072 bit — niedopuszczalny - Curve25519 / ChaCha20 — nie jest certyfikowany FIPS, niedopuszczalny w SYLION (nawet jeśli silny kryptograficznie)

Propozycje IKE i ESP muszą zawierać wyłącznie algorytmy z profilu — nie dopuszcza się negocjacji w dół (downgrade). Konfiguracja strongSwan: proposals = aes256gcm16-sha384-ecp384 (jedna propozycja, brak alternatyw).

34.3. Czasy życia SA i rekeying

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 34.1, 34.2, 33.5

Security Association (SA) w IPsec ma ograniczony czas życia. Po wygaśnięciu SA musi nastąpić rekeying — ustanowienie nowej SA z nowymi kluczami sesyjnymi. Rekeying jest krytyczny dla PFS (Perfect Forward Secrecy) — kompromitacja klucza jednej SA nie ujawnia ruchu szyfrowanego innymi SA.

Parametry SA:

Parametr	Wartość	Uwagi
IKE SA lifetime	14400 s (4h)	Pełna renegotiacja IKE
IKE SA rekey	12000 s (3h 20min)	Rozpoczęcie rekeying przed wygaśnięciem
IKE SA rekey jitter	600 s (10 min)	Losowy offset, unikanie synchronizacji
Child SA lifetime (time)	3600 s (1h)	Rekeying ESP SA
Child SA rekey	3000 s (50 min)	Rozpoczęcie rekeying ESP
Child SA rekey jitter	300 s (5 min)	Losowy offset
Child SA lifetime (bytes)	4 GiB	Rekeying po przesłaniu 4 GiB danych
DPD delay	30 s	Interwał Dead Peer Detection
DPD timeout	150 s	Timeout DPD przed restart

PFS (Perfect Forward Secrecy): PFS jest wymagany — każdy rekeying Child SA wymaga nowej wymiany Diffie-Hellman (ECP-384). Konfiguracja strongSwan: esp_proposals = aes256gcm128-sha384-ecp384 (obecność grupy DH w propozycji ESP wymusza PFS).

Rekeying behavior: - Rekeying jest inicjowany przez stronę, której timer wygaś wcześniej (jitter zapewnia, że jedna strona inicjuje) - Podczas rekeying stara SA jest utrzymywana do momentu ustanowienia nowej — brak utraty pakietów - Jeśli rekeying nie powiedzie się 3 razy — SA jest zamykana i inicjowana nowa od zera (pełny IKE handshake) - Logi rekeying są przekazywane do SIEM — brak udanego rekeying w ciągu 2× lifetime generuje alert

Dla tieru STATE rozważany jest skrócony lifetime: IKE SA 7200 s (2h), Child SA 1800 s (30 min) — zapewnia szybszą rotację kluczy kosztem większego narzutu obliczeniowego.

34.4. NAT-T i CGNAT

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 34.1, 33.5, 34.9

NAT Traversal (NAT-T, RFC 3947/3948) jest mechanizmem umożliwiającym działanie IPsec przez urządzenia NAT — routery domowe, firewalle korporacyjne, CGNAT operatorów ISP.

Problem: Protokół ESP (Encapsulating Security Payload) nie posiada numerów portów — urządzenia NAT nie potrafią go poprawnie obsłużyć. NAT-T rozwiązuje to przez enkapsulację pakietów ESP w UDP na porcie 4500.

Konfiguracja w SYLION: - NAT-T jest domyślnie włączony na routerze i G1 - Port: UDP 4500 (standard), UDP 500 (IKE negocjacja) - Detekcja NAT: IKEv2 automatycznie wykrywa obecność NAT podczas handshake (NAT_DETECTION_SOURCE_IP / DESTINATION_IP payloads) - Keepalive: co 20 sekund (utrzymanie mapowania NAT na routerze ISP)

CGNAT (Carrier-Grade NAT): Wielu operatorów ISP (szczególnie mobilnych) stosuje CGNAT — adres publiczny jest współdzielony przez wielu klientów. Specyfika CGNAT: - Mapowanie portów może się zmieniać — NAT-T keepalive musi być częsty (20s) - Niektóre CGNAT filtrują UDP 4500 — w takim przypadku: próba port 443 (encapsulation over HTTPS — eksperymentalne) lub fallback na LTE z innym operatorem - Ograniczenie sesji: CGNAT może limitować liczbę jednoczesnych sesji UDP — IPsec IKEv2 używa jednej sesji (OK) - Timeout: CGNAT timeout dla UDP bywa krótki (30–120 sekund) — keepalive 20s jest wystarczający

Diagnostyka NAT-T: Router loguje status NAT-T: "NAT detected on remote side" / "NAT detected on local side". Logi są dostępne w SIEM. Problem z NAT-T jest częstą przyczyną awarii tunelu w środowiskach hotelowych i korporacyjnych — playbook diagnostyczny obejmuje: sprawdzenie portów 500/4500, test z inną siecią, test z LTE.

34.5. mTLS dla połączeń wewnętrznych

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 34.1, 43.10, 47.4

Wszystkie połączenia wewnętrzne (service-to-service) w infrastrukturze SYLION poza tunelem IPsec muszą być chronione przez mutual TLS (mTLS) — obustronne uwierzytelnienie certyfikatami X.509 na warstwie TLS.

Zakres mTLS: - Komunikacja między komponentami w Zone 3 ↔ Zone 4 (workloady ↔ usługi wspólne) - Komunikacja w obrębie Zone 4 (service ↔ service) - Komunikacja Zone 4 ↔ Zone 5 (usługi ↔ management) - API G2 ↔ workloady - API Session Broker ↔ G2

Konfiguracja mTLS: - Protokół: TLS 1.3 (wyłącznie). TLS 1.2 dopuszczalny jako fallback wyłącznie dla integracji z systemami legacy (wymaga uzasadnienia i akceptacji ryzyka) - Ciphersuite: TLS_AES_256_GCM_SHA384, TLS_CHACHA20_POLY1305_SHA256 (drugi jako fallback) - Certyfikaty: wystawiane przez wewnętrzną CA SYLION (Rozdział 47), krótkie czasy życia (24–72h, automatyczna rotacja) - Weryfikacja: pełna walidacja łańcucha certyfikatów, sprawdzenie CRL/OCSP, weryfikacja CN/SAN - Certificate pinning: opcjonalny — dla krytycznych połączeń (G2 ↔ Session Broker)

Service mesh: Dla złożonych topologii usług wewnętrznych rekomendowane jest wdrożenie service mesh (np. Istio/Envoy sidecar) zarządzającego mTLS automatycznie. Service mesh zapewnia: automatyczną rotację certyfikatów, circuit breaking, obserwowalność (distributed tracing), egzekwowanie polityk sieciowych.

W przypadku braku service mesh — mTLS musi być skonfigurowany ręcznie dla każdego połączenia. Certyfikaty krótkoterminowe (24–72h) wymagają automatyzacji rotacji (cert-manager lub analogiczny system).

34.6. QoS dla kanałów uprzywilejowanych

Status: [R] Rekomendowany Odbiorca: Administrator, Architekt Wpływ na baseline: Średni Powiązane rozdziały: 34.1, 41.1, 37.5

Quality of Service (QoS) w kontekście SYLION oznacza priorytetyzację ruchu w tunelu IPsec, aby zapewnić jakość usług krytycznych — przede wszystkim voice/video i streaming obrazu — kosztem ruchu mniej wymagającego latencji.

Klasy ruchu w tunelu SYLION:

Klasa	DSCP	Priorytet	Przykładowy ruch
Voice/RTP	EF (46)	Najwyższy	Połączenia głosowe, audio brokera
Budżet latencji vo	ice per-hop:**		
Komponent Target ——— —— Pixel audio capturer Remote client enco IPsec VPN overhead G1/G2 transit 10 Session broker 2 env-matrix/env-sig Internet path 40 SUMA (one-way) SUMA (round-trip) Próg krytyczny**	latencji ——— e 10–20 ms de 20 ms 5–10 ms ~20 ms 0–30 ms nał processing 1 ~60 ms ~130 ms)** ~260 ms <300 ms RTT		
arlink: mediana la	tencji USA ~46ms (	Ookla Q1 2025), me	diana Europa ~80-98ms (IFIP Networking 2025), jitter typowo <10ms ale skoki 30-50ms podczas handoverów satelitarnych, utrata pakietów średnio 1-4%.
Video/RTP	AF41 (34)	Wysoki	Wideo konferencyjne
Session streaming	AF31 (26)	Wysoki	Piksele z Session Broker
Interactive	AF21 (18)	Średni	Klawiatura, mysz, schowek
Bulk/file transfer	BE (0)	Niski	Transfer plików (CDR pipeline)

Implementacja QoS: Na routerze: pakiety są oznaczane odpowiednim DSCP na podstawie portu docelowego i protokołu. Kolejowanie: fq_codel lub cake (SQM — Smart Queue Management) z priorytetyzacją DSCP.

Na G1: pakiety z tunelu są dekapsulowane i zachowują oznaczenia DSCP. Dalsze routowanie w Zone 2/3 respektuje QoS.

Ograniczenia: QoS działa efektywnie wyłącznie na łączu kontrolowanym — tj. na odcinku router ↔ G1. Na łączu ISP (WAN) DSCP mogą być ignorowane lub resetowane przez operatora ISP. Dlatego SQM na routerze (kształtowanie ruchu wychodzącego do szybkości uploadu łącza minus margines) jest kluczowy — zapobiega buforowaniu na urządzeniach ISP (bufferbloat), które niszczą QoS.

Konfiguracja SQM na routerze: tc lub cake z parametrami: bandwidth = 90% uploadu łącza, fairness per-flow, wash DSCP = no (zachowanie oznaczeń).

34.7. Polityki routingu DNS

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 33.7, 34.1, 43.7

DNS routing w SYLION jest zaprojektowany tak, aby zapytania DNS nigdy nie opuszczały tunelu IPsec i trafiały wyłącznie do kontrolowanych serwerów DNS.

Architektura:

Terminal → Router (dnsmasq :53) → [tunel IPsec] → G1 → Zone 4 DNS (Unbound/CoreDNS)

Polityki: 1. Terminal konfigurowany przez DHCP routera: DNS = IP routera na br-lan (np. 192.168.10.1) 2. Router: dnsmasq forwarduje do 10.x.x.53 (DNS SYLION w Zone 4) przez tunel 3. Zapytania DNS poza tunelem — blokowane przez kill switch 4. Split DNS: domeny wewnętrzne SYLION (*.sylion.internal) → resolver wewnętrzny; wszystkie inne → resolver z filtracją threat intelligence

Zone 4 DNS resolver: - Unbound lub CoreDNS z DNSSEC validation - Filtracja: RPZ (Response Policy Zone) z listami malware/phishing (aktualizowane co 4h z threat intel feeds) - Logowanie: per-operator query logging (opcjonalnie — konfigurowane przez politykę organizacyjną) - Cache: TTL respektowany, min. 60s, max. 86400s - Upstream: recursive resolver lub forwarding do zaufanego upstream (np. Quad9 9.9.9.9 z DNSSEC)

DNS override (specjalne przypadki): Administrator może skonfigurować DNS override dla konkretnych domen — np. przekierowanie domeny SaaS do wewnętrznego proxy lub blokada konkretnych domen per operator/tier.

34.8. Wybór ścieżki i failover

Status: [R] Rekomendowany Odbiorca: Administrator, Architekt Wpływ na baseline: Średni Powiązane rozdziały: 34.1, 34.4, 33.15

W scenariuszach z wieloma dostępnymi łączami (Ethernet, Wi-Fi, LTE) router SYLION powinien automatycznie wybierać optymalną ścieżkę i przełączać się na backup w razie awarii.

Priorytet ścieżek (domyślny): 1. Ethernet WAN (najniższa latencja, najwyższa przepustowość, najwyższa niezawodność) 2. Wi-Fi WAN (WISP — połączenie do istniejącej sieci Wi-Fi) 3. LTE/5G (modem USB podłączony do routera) 4. Starlink (jeśli dostępny — moduł autonomiczny 33.15)

Failover logic: Router monitoruje status łącza WAN: - Ping do G1 co 10 sekund (przez interfejs WAN, poza tunelem — ICMP echo) - Jeśli 3 kolejne pingi failed — uznanie łącza za down - Przełączenie na następne łącze z listy priorytetów - IPsec IKEv2 MOBIKE (RFC 4555) zapewnia bezstratne przełączenie tunelu na nowy adres IP — sesja operatora nie jest przerywana

Failback: Po przywróceniu łącza o wyższym priorytecie — automatyczny failback (powrót na lepsze łącze). Konfigurowalny delay: 60 sekund stabilności przed failback (unikanie flapping).

Multi-WAN (zaawansowany): Dla scenariuszy wymagających wysokiej dostępności — router z dwoma interfejsami WAN (Ethernet + LTE) może utrzymywać dwa tunele IPsec jednocześnie (active-passive lub active-active z ECMP). Konfiguracja advanced — wymaga routera z wystarczającą ilością RAM i CPU.

MOBIKE jest kluczowym mechanizmem — operator nie zauważa przełączenia ścieżki. Sesja streamingowa (Session Broker) kontynuuje działanie na nowym tunelu. Jedyń objaw: krótki (< 5s) wzrost latencji podczas przełączenia.

34.9. Łączność LTE/5G

Status: [R] Rekomendowany Odbiorca: Administrator, Operator Wpływ na baseline: Średni Powiązane rozdziały: 34.1, 34.4, 33.15

LTE/5G jest preferowanym łączem mobilnym dla operatorów SYLION pracujących w terenie. Modem LTE jest podłączany do routera przez port USB.

Wymagania modemu: - Obsługa LTE Cat 6+ (download ≥ 300 Mbps, upload ≥ 50 Mbps) — wystarczające dla sesji streamingowej - Opcjonalnie: 5G NSA/SA dla wyższej przepustowości i niższej latencji - Obsługa przez OpenWrt (sterownik: QMI, MBIM lub NCM) - Dual SIM (rekomendowane) — dwa operatory na wypadek awarii jednego

Kwestie bezpieczeństwa LTE/5G: - CGNAT jest standardem u operatorów mobilnych — NAT-T (34.4) jest niezbędny - Ruch jest szyfrowany na warstwie radiowej (LTE: AES-128, 5G: AES-256/SNOW), ale operator sieci ma dostęp do ruchu — dlatego tunel IPsec jest wymagany - IMSI catcher / rogue BTS — patrz moduł autonomiczny 33.15 [A] - SIM swap attack — ryzyko dla operatorów używających SMS jako kanału awaryjnego. W SYLION SMS nie jest używany do uwierzytelnienia — ryzyko ograniczone do utraty łączności

Konfiguracja: Router: modem LTE jako interfejs WAN (wwan0/usb0). Konfiguracja APN, PIN SIM, preferowana sieć (LTE only / 5G preferred) — wszystko w konfiguracji OpenWrt. Tunel IPsec jest ustanawiany przez interfejs LTE tak samo jak przez Ethernet — konfiguracja strongSwan jest agnostyczna względem warstwy fizycznej.

34.10. Łączność Wi-Fi

Status: [R] Rekomendowany Odbiorca: Administrator, Operator Wpływ na baseline: Średni Powiązane rozdziały: 34.1, 34.8, 33.8

Wi-Fi jest najczęstszym łączem operatorów SYLION pracujących z biura, domu lub lokalizacji tymczasowej (hotel, coworking). Router SYLION może łączyć się z istniejącą siecią Wi-Fi w trybie WISP (Wireless ISP client).

Tryb WISP: Router używa radia Wi-Fi w trybie STA (station/client) na interfejsie WAN, łącząc się z siecią hosta (hotel, biuro). Jednocześnie radio tworzy własny AP (Access Point) na interfejsie LAN dla terminala SYLION. W modelu GL-iNet MT-3000 z Wi-Fi 6 oba tryby (STA + AP) działają na tym samym chipie z minimalnym spadkiem wydajności.

Kwestie bezpieczeństwa Wi-Fi: - Sieć Wi-Fi hosta jest traktowana jako nieprzyjazna (hostile network — 34.12). Cały ruch jest chroniony tunelem IPsec — nawet jeśli Wi-Fi jest otwarte (bez hasła) lub skompromitowane - Evil twin attack — napastnik tworzy sieć o tej samej nazwie co hotel/biuro. Ochrona: tunel IPsec z uwierzytelnieniem certyfikatem X.509 — nawet jeśli terminal połączy się z evil twin, napastnik nie jest w stanie podszyć się pod G1 - Captive portal (portal logowania hotelowego) — problematyczny: kill switch blokuje ruch poza tunelem, a captive portal wymaga HTTP na port 80/443. Rozwiązanie: router ma tryb „captive portal passthrough” — tymczasowe dopuszczenie ruchu HTTP z jednego urządzenia (terminala) na 5 minut, wyłącznie do IP gateway sieci Wi-Fi. Po zalogowaniu w portalu — tryb wyłączany, kill switch pełny - Wi-Fi deauth attack — napastnik rozłącza terminal z AP. Ochrona: Wi-Fi 6 (802.11ax) z PMF (Protected Management Frames, 802.11w) — wymagane na AP routera SYLION

Konfiguracja: Operator łączy router z siecią Wi-Fi hosta: (a) przez aplikację GL-iNet, (b) przez klienta SSH, (c) przez LuCI (jeśli aktywne). SSID i hasło sieci hosta są przechowywane tymczasowo w konfiguracji routera — po rozłączeniu mogą być usunięte automatycznie (opcja konfiguracyjna).

34.11. Łączność satelitarna (Starlink)

Status: [O] Opcjonalny Odbiorca: Administrator, Architekt Wpływ na baseline: Niski Powiązane rozdziały: 34.1, 34.8, 33.15

Starlink zapewnia łączność internetową przez konstelację satelitów LEO (Low Earth Orbit) i jest opcjonalnym łączem dla operatorów SYLION w lokalizacjach bez dostępu do internetu kablowego lub komórkowego.

Specyfika Starlink: latencja mediana ~46ms USA / ~80ms EU (Ookla Q1 2025 / IFIP Networking 2025), okazjonalnie >200ms przy handoffach satelitarnych (LEO), okazjonalnie > 100 ms (obstrukcje, handoff między satelitami). Akceptowalne dla sesji streamingowej i voice — poniżej progu 150 ms E2E - Przepustowość: 50–200 Mbps download, 10–40 Mbps upload. Wystarczająca dla sesji streamingowej (wymagane: min. 5 Mbps upload, 10 Mbps download) - CGNAT: Starlink stosuje CGNAT — NAT-T (34.4) jest wymagany - Jitter: wyższy niż łącza kablowe — QoS (34.6) i buforowanie po stronie Session Broker są kluczowe - Zmienność IP: adres IP zmienia się przy handoff — MOBIKE (34.8) zapewnia ciągłość tunelu

Konfiguracja: Router SYLION jest podłączony do routera Starlink przez Ethernet (bridge mode na routerze Starlink). Router SYLION traktuje Starlink jak zwykłe łącze Ethernet WAN. Konfiguracja IPsec jest identyczna — strongSwan nie rozróżnia medium fizyczne.

Ograniczenia: - Starlink wymaga widoczności nieba — nie działa w budynkach bez anteny zewnętrznej - W niektórych krajach Starlink nie jest dostępny lub wymaga pozwolenia - Starlink Inc. (SpaceX) jest podmiotem amerykańskim — ruch przechodzi przez infrastrukturę amerykańską. Tunel IPsec chroni treść, ale metadane (IP źródłowy/docelowy, wolumen ruchu) są widoczne dla Starlink. Dla tieru STATE — rozważenie ryzyka geopolitycznego

34.12. Łączność w sieciach wrogich (hostile network)

Status: [N] Normatywny Odbiorca: Operator, Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 34.1, 34.10, 33.6

Architektura SYLION zakłada, że każda sieć pomiędzy terminalem a G1 jest potencjalnie wroga (hostile network model). Oznacza to, że projektowanie bezpieczeństwa nie opiera się na zaufaniu do sieci lokalnej, ISP czy jakiegokolwiek pośrednika.

Scenariusze hostile network: 1. Otwarte Wi-Fi (hotel, lotnisko, kawiarnia) — brak szyfrowania, pełna widoczność ruchu 2. Evil twin AP — fałszywy punkt dostępowy imitujący sieć hosta 3. Korporacyjny firewall z deep packet inspection — inspekcja TLS (MITM proxy) 4. ISP z MITM — operator ISP lub rządowy przechwytyjący ruch 5. Captive portal z wstrzykiwaniem JavaScript — modyfikacja stron HTTP 6. DNS poisoning — fałszywe odpowiedzi DNS 7. BGP hijack — przekierowanie ruchu na poziomie routingu internetowego

Ochrona SYLION: Wszystkie powyższe scenariusze są neutralizowane przez: - Tunel IPsec IKEv2 z uwierzytelnieniem certyfikatem — napastnik nie może podszyć się pod G1 (wymagany certyfikat wystawiony przez CA SYLION) - Kill switch — brak ruchu poza tunelem (nawet jeśli napastnik kontroluje sieć) - DNS przez tunel — brak możliwości DNS poisoning - NAT-T — ruch wygląda jak UDP na porcie 4500 — większość firewalli przepuszcza

Scenariusz problematyczny: blokada IPsec Niektóre sieci (korporacyjne firewalle, sieci w krajach z cenzurą) mogą blokować UDP 500/4500 lub protokół ESP. W takim przypadku: - Opcja 1: przejście na łącze LTE (ominięcie firewalla korporacyjnego) - Opcja 2: IPsec-over-TCP (port 443) — strongSwan obsługuje plugin socket-tcpext. Mniej wydajne (TCP-over-TCP problem), ale omija większość blokad - Opcja 3 [E]: obfuscation (maskowanie ruchu jako HTTPS) — eksperymentalne, nie w baseline

Operator powinien dysponować instrukcją postępowania dla każdego z powyższych scenariuszy. Instrukcja jest częścią zestawu operatora (operator kit) dostarczanego przy onboardingu.

34.13. Monitorowanie parametrów sieci

Status: [N] Normatywny Odbiorca: Administrator, SOC Wpływ na baseline: Średni Powiązane rozdziały: 34.1, 34.6, 41.13

Monitorowanie parametrów sieci jest niezbędne do zapewnienia jakości sesji operatora i wczesnego wykrywania problemów.

Metryki monitorowane przez router:

Metryka	Interwał	Próg alertu	Źródło
RTT do G1 (ping)	10 s	> 200 ms (ciągły > 60 s)	Router
Packet loss	10 s	> 2% (ciągły > 60 s)	Router
Jitter	10 s	> 30 ms (ciągły > 60 s)	Router
Przepustowość upload	300 s	< 5 Mbps	Router
Przepustowość download	300 s	< 10 Mbps	Router
Status tunelu IPsec	30 s (DPD)	DOWN	Router / strongSwan
Rekey success/failure	event	Failure	strongSwan log
NAT-T status	event	Change	strongSwan log
Wi-Fi RSSI (jeśli WISP)	60 s	< -75 dBm	Router
LTE RSRP (jeśli modem)	60 s	< -110 dBm	Modem AT

Raportowanie: Metryki są przesyłane przez tunel IPsec do systemu SIEM/monitoring w Zone 5 (np. Prometheus + Grafana, lub agent telegraf). Format: JSON lub Prometheus exposition format.

Automatyczne reakcje: - RTT > 200 ms ciągły > 60 s → powiadomienie operatora: „Jakość łącza obniżona — rozważ zmianę sieci” - Packet loss > 5% ciągły > 30 s → Session Broker obniża jakość streamu (adaptacyjny bitrate) - Tunel DOWN > 30 s → alerty do SOC, operator widzi komunikat „Brak połączenia — trwa ponowne łączenie” - Wi-Fi RSSI < -80 dBm → sugestia przejścia na LTE

Monitoring sieci jest integralną częścią playbooku degradacji jakości (41.14) — dane sieciowe korelowane z metrykami medialnymi (jitter, packet loss audio/video) pozwalają na szybką identyfikację przyczyny problemu.

Rozdział 35. G1 — Network Gateway

35.1. Rola G1 w architekturze

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 33.5, 34.1, 36.1

G1 (Network Gateway) jest pierwszą bramą infrastruktury SYLION — publicznym punktem styku z internetem, odpowiedzialnym za terminację tuneli IPsec IKEv2 od routerów operatorskich. G1 rezyduje w Zone 2 (strefa bram) i stanowi granicę między siecią publiczną a kontrolowaną infrastrukturą SYLION.

G1 nie podejmuje decyzji autoryzacyjnych — jest to wyłączna kompetencja G2 (Rozdział 36). G1 zajmuje się wyłącznie: 1. Terminacją tuneli IPsec IKEv2 (uwierzytelnienie certyfikatem X.509) 2. Weryfikacją integralności ruchu (ESP: szyfrowanie + integralność AEAD) 3. Filtracją na poziomie sieci (ACL, firewall, rate limiting) 4. Przekazywaniem zdekapitulowanego ruchu do G2 lub bezpośrednio do Session Broker (w zależności od architektury) 5. Telemetrią sieciową (NetFlow/IPFIX, logi IKE)

Zasada minimalizmu G1: „G1 widzi pakiety, ale nie rozumie sesji.” G1 operuje na warstwie 3–4 (sieciowej/transportowej) i nie analizuje treści — nie ma dostępu do danych aplikacji, nie przechowuje artefaktów, nie loguje treści komunikacji.

G1 jest komponentem o najwyższym narażeniu (publicly exposed) — dlatego podlega najsurowszemu hardening: - Minimalny system operacyjny (Linux hardened, immutable rootfs) - Brak usług poza strongSwan + firewall + telemetria - Brak kont użytkowników (dostęp wyłącznie przez bastion w Zone 5) - Brak przechowywania danych (stateless — poza aktywnym stanem SA)

35.2. Zakres odpowiedzialności

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 35.1, 36.1, 37.1

Precyzyjne rozgraniczenie odpowiedzialności między G1 a innymi komponentami jest kluczowe dla bezpieczeństwa i utrzymania:

G1 odpowiada za: - Terminację IPsec IKEv2 SA (IKE + Child SA) - Weryfikację certyfikatu klienta (router) — łańcuch zaufania do CA SYLION - Sprawdzenie CRL / OSCP statusu certyfikatu klienta - Dekapsulację ESP — odszyfrowanie i weryfikacja integralności pakietów - Firewall: ACL na wejściu (przed dekapitulacją: IP source, protocol, port) i na wyjściu (po dekapitulacji: reguły per tunel) - Rate limiting na poziomie per-tunel i globalnym - Anti-DDoS na warstwie sieciowej (SYN flood protection, UDP flood limiting) - Przekazywanie ruchu do Zone 2 inner network (do G2 lub Session Broker) - Telemetria: NetFlow/IPFIX, logi IKE (SA establishment, rekey, failure), metryki (liczba aktywnych SA, przepustowość, packet rate)

G1 NIE odpowiada za: - Autoryzację operatora (→ G2) - Weryfikację device posture (→ G2) - Kontrolę sesji (→ Session Broker) - Logikę biznesową — jakkolwiek - Przechowywanie danych — jakkolwiek - Routing aplikacyjny — jakkolwiek

Rozgraniczenie to jest celowe — G1 jest „głupią bramą sieciową” (dumb gateway), co minimalizuje powierzchnię ataku. Im mniej logiki na G1, tym mniejsze ryzyko błędu w najbardziej narażonym komponencie.

35.3. Terminacja tuneli

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 33.5, 34.1, 34.2

G1 terminuje tunele IPsec IKEv2 od routerów operatorskich. Konfiguracja G1 strongSwan (serwer):

```
connections {
  sylion-operators {
    version = 2
    local_addr = <G1_PUBLIC_IP>
    local {
      auth = pubkey
      certs = g1-cert.pem
      id = "C=PL, O=SYLION, CN=g1.sylion.example.com"
    }
    remote {
      auth = pubkey
      cacerts = sylion-ca.pem
      # Każdy router z certyfikatem od SYLION CA jest dopuszczony
    }
    children {
      operator-tunnel {
        local_ts = 10.0.0.0/8
        remote_ts = dynamic
        esp_proposals = aes256gcm128-sha384-ecp384
        life_time = 3600
        rekey_time = 3000
        dpd_action = clear
      }
      proposals = aes256-sha384-ecp384
      rekey_time = 14400
      dpd_delay = 30
      dpd_timeout = 150
      pools = operator-pool
    }
    pools {
      operator-pool {
        addr = 10.100.0.0/16
        dns = 10.0.4.53, 10.0.4.54
      }
    }
  }
}
```

Kluczowe elementy: - Uwierzytelnienie: certyfikaty X.509 — router przedstawia certyfikat klienta, G1 weryfikuje łańcuch do CA SYLION i sprawdza CRL - Pula adresów: G1 przydziela adres IP z puli 10.100.0.0/16 (konfigurowalny) dla każdego tunelu. Adres jest stały per operator (mapowanie w bazie) lub dynamiczny (pool) - Traffic selectors: G1 → operator: 10.0.0.0/8 (cała infrastruktura wewnętrzna). Operator → G1: dynamiczny (adres przydzielony z puli) - DPD action: clear — po stronie serwera: jeśli router nie odpowiada na DPD, SA jest usuwana (zwolnienie zasobów)

Skalowalność: Jeden G1 obsługuje do ~10 000 jednoczesnych tuneli (zależne od hardware — CPU z AES-NI, RAM). Powyżej — horizontal scale-out (35.10).

Certyfikat G1: Certyfikat G1 jest wystawiony przez CA SYLION i zawiera: CN = FQDN G1 (np. g1.sylion.example.com), SAN = IP publiczne G1. Certyfikat jest rotowany co 90 dni (STANDARD/PRO), co 30 dni (STATE).

35.4. ACL i firewall

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 35.1, 35.5, 33.6

Firewall G1 (nftables) implementuje wielowarstwową filtrację:

Warstwa zewnętrzna (WAN → G1):

```
chain input_wan {
  # IKE udp dport { 500, 4500 } accept
  # ESP ip protocol esp accept
  # ICMP (ograniczony — DDoS) icmp type echo-request limit rate 10/second
  accept
  # Wszystko inne — drop
  drop
}
```

Warstwa wewnętrzna (po dekapitulacji, ruch z tunelu):

```
chain forward_tunnel {
  # Ruch z operatora (10.100.x.x) do G2 ip saddr 10.100.0.0/16 ip daddr 10.0.2.0/24 accept
  # Ruch z operatora do Session Broker ip saddr 10.100.0.0/16 ip daddr 10.0.3.0/24 tcp dport { 443, 8443 } accept
  # Ruch z operatora do DNS ip saddr 10.100.0.0/16 ip daddr { 10.0.4.53, 10.0.4.54 } udp dport 53
  accept
  # Wszystko inne — drop + log
  log prefix "G1-FWD-DROP: "
  drop
}
```

Kluczowe zasady: - Default DROP na wszystkich chain (input, forward, output) - Ruch z tunelu jest dozwolony wyłącznie do G2, Session Broker i DNS — żaden inny zasób wewnętrzny nie jest bezpośrednio dostępny z tunelu - Ruch między tunelami (operator ↔ operator) jest bezwzględnie zablokowany — mikrosegmentacja per operator (38.1) - Logi DROP są przekazywane do SIEM (rate limited, aby nie zalać logu)

Per-operator ACL: G1 może implementować per-operator ACL na podstawie adresu IP przydzielonego z puli. Np. operator z tieru STANDARD ma dostęp tylko do podzbioru usług; operator STATE ma dostęp do dodatkowych endpointów. Implementacja: nftables z setami per tier lub dynamiczne reguły ładowane przy ustanowieniu SA (updown script).

35.5. Rate limiting i ochrona anty-DDoS

Status: [N] Normatywny Odbiorca: Administrator, SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 35.4, 35.6, 50.1

G1 jest publicznym endpointem — narażonym na ataki DDoS (Distributed Denial of Service). Ochrona anty-DDoS jest wielowarstwowa:

Warstwa 1 — ISP/Cloud provider: Przed G1 powinien znajdować się system filtracji volumetrycznych ataków DDoS: - Scrubbing service (np. Cloudflare Spectrum, AWS Shield Advanced, dedykowany scrubber) - BGP blackhole/flowspec dla ataków > 10 Gbps - Geo-blocking (opcjonalnie — ograniczenie ruchu do krajów, z których łączą się operatorzy)

Warstwa 2 — G1 firewall (nftables):

Rate limit IKE_INIT (nowe połączenia) udp dport 500 ct state new limit rate 100/second accept udp dport 500 ct state new drop # Rate limit per source IP set rate_limit_ike { type ipv4_addr flags dynamic,timeout timeout 60s } udp dport 500 ct state new add @rate_limit_ike { ip saddr limit rate 5/second } accept udp dport 500 ct state new drop # SYN flood protection (jeśli TCP jest używany) tcp flags syn limit rate 1000/second accept

Warstwa 3 — strongSwan: - half_open_timeout = 30 — SA w stanie half-open (IKE_SA_INIT bez IKE_AUTH) są usuwane po 30 sekundach - cookie_threshold = 10 — po 10 jednoczesnych half-open SA, strongSwan wymaga IKEv2 cookie (ochrona przed spoofed IP SYN-flood equivalent) - block_threshold = 100 — po 100 nieudanych prób z jednego IP — tymczasowa blokada (60 sekund)

Monitoring: - Metryki: liczba aktywnych SA, tempo nowych SA/s, liczba half-open SA, packet rate na interfejsie WAN - Alert: half-open SA > 50, nowe SA/s > 200, packet rate > 100k pps → alert DDoS w SIEM - Automatyczna reakcja: eskalacja do ISP/scrubber, aktywacja dodatkowych reguł filtracji

35.6. Telemetria sieciowa

Status: [N] Normatywny Odbiorca: Administrator, SOC Wpływ na baseline: Średni Powiązane rozdziały: 35.1, 34.13, 46.6

G1 generuje telemetrię sieciową niezbędną do monitorowania, troubleshootingu i detekcji anomalii.

Typy telemetrii:

Typ	Format	Interwał	Cel
NetFlow/IPFIX	v9/v10	co 60 s lub per-flow	Analiza ruchu, anomalie
IKE logs	syslog (JSON)	event-driven	Audyt SA, troubleshooting
Metryki strongSwan	Prometheus	co 15 s	Monitoring operacyjny
Firewall logs	syslog	event (DROP only)	Detekcja ataków
System metrics	Prometheus (node_exporter)	co 15 s	Zdrowie hosta

NetFlow/IPFIX: G1 eksportuje rekordy przepływów (flow records) do kolektora w Zone 5. Rekord zawiera: src IP, dst IP, src port, dst port, protocol, bytes, packets, timestamps. Nie zawiera payloadu — wyłącznie metadane sieciowe. NetFlow jest kluczowy do: (a) wykrywania anomalii (nietypowe wolumeny ruchu), (b) capacity planning, (c) forensics (kto łączył się kiedy).

IKE logs: Logi strongSwan (charon) w formacie JSON: SA establishment (sukces/failure z przyczyną), rekey (sukces/failure), DPD events, certificate validation (sukces/failure z detalami). Logi są krytyczne dla troubleshootingu i detekcji prób nieautoryzowanego dostępu (nieznany certyfikat, wygasły certyfikat, nieprawidłowy CA).

Metryki: Endpoint Prometheus (port wewnętrzny, niedostępny z WAN): - ipsec_sa_active — liczba aktywnych SA - ipsec_sa_halfopen — liczba half-open SA - ipsec_bytes_in/out — wolumen ruchu per SA - ipsec_rekey_success/failure — liczniki rekey - g1_cpu_usage, g1_mem_usage, g1_net_rx/tx — metryki systemowe

35.7. Minimalny zestaw usług

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 35.1, 35.2, 46.1

G1 uruchamia wyłącznie następujące usługi:

Usługa	Proces	Port	Kierunek
strongSwan (IKE)	charon-systemd	UDP 500, 4500 (WAN)	Inbound
nftables (firewall)	kernel (netfilter)	N/A	N/A
NetFlow exporter	softflowd lub pmacctd	UDP (wewnętrzny) → Zone 5	Outbound
Prometheus node_exporter	node_exporter	TCP (wewnętrzny) → Zone 5	Outbound
Syslog forwarder	rsyslog	TCP/TLS (wewnętrzny) → Zone 5	Outbound
NTP client	chrony	UDP 123 (wewnętrzny) → Zone 5	Outbound
SSH (bastion only)	sshd	TCP (wewnętrzny, z Zone 5)	Inbound

Żadna inna usługa nie jest dozwolona. Brak: serwera HTTP/S, bazy danych, kontenera, agenta zarządzania z dostępem z WAN. Dostęp SSH jest możliwy wyłącznie z bastion host w Zone 5 (46.2).

System operacyjny G1: Linux (np. Debian minimal, Alpine, lub custom image) z immutable rootfs. Kernel hardened: KASLR, stack canaries, KPTI, disabled modules loading. SELinux lub AppArmor w trybie enforcing.

35.8. Dane niedopuszczone na G1

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 35.1, 35.2, 42.1

G1 nie przechowuje i nie przetwarza następujących danych: - Dane aplikacyjne operatorów (dokumenty, pliki, komunikacja) - Dane tożsamości operatorów (hasła, tokeny OIDC, FIDO2 credentials) - Dane sesji (session tokens, clipboard, screen capture) - Dane biznesowe (CRM, bazy danych, raporty) - Logi treści komunikacji

G1 przechowuje wyłącznie: - Certyfikat G1 i klucz prywatny (chroniony: permissions 0600, właściciel root) - Certyfikat CA SYLION (do weryfikacji certyfikatów klientów) - CRL (Certificate Revocation List) — cache, aktualizowany co 1h z Zone 5 - Konfigurację strongSwan i nftables (read-only, zarządzana z Zone 5) - Tymczasowy stan SA (w pamięci RAM — utracony przy restarcie)

Po restarcie G1 traci wszystkie aktywne SA — routery operatorskie automatycznie ponownie ustanawiają tunele (DPD detect + restart action). Dane nie są persistowane na dysku poza konfiguracją i certyfikatami.

35.9. Sekrety i certyfikaty G1

Status: [N] Normatywny Odbiorca: Administrator, PKI Officer Wpływ na baseline: Krytyczny Powiązane rozdziały: 35.3, 47.3, 47.5

Sekrety przechowywane na G1:

Sekret	Typ	Ochrona	Rotacja
Klucz prywatny G1 (ECDSA P-384)	Plik PEM	Permissions 0600, root only. Dla STATE: HSM (PKCS#11)	180 dni (STANDARD/PRO), 90 dni (STATE)
Certyfikat G1 (X.509)	Plik PEM	Public — nie wymaga ochrony	Zgodnie z kluczem
Certyfikat CA SYLION	Plik PEM	Public	Root CA: 10 lat, Intermediate: 2 lata
CRL	Plik PEM/DER	Cache, aktualizowany co 1h	Continuous

Dla tieru STATE: Klucz prywatny G1 powinien rezydować w HSM (Hardware Security Module) podłączonym do G1. strongSwan obsługuje PKCS#11 — klucz nigdy nie opuszcza HSM, operacje kryptograficzne (podpis IKE_AUTH, DH) wykonywane są na HSM.

HSM dla G1: CloudHSM (AWS), Dedicated HSM (Azure), on-prem HSM (Thales Luna, Utimaco) podłączony przez sieć wewnętrzną. Wybór zależy od modelu deployment.

Procedura kompromitacji klucza G1: 1. Natychmiastowe unieważnienie certyfikatu G1 (CRL + OCSP) 2. Generowanie nowego klucza i certyfikatu 3. Wdrożenie nowego certyfikatu na G1 (lub failover G1 z nowym kluczem) 4. Notyfikacja routerów operatorskich o zmianie certyfikatu (automatyczna — routery weryfikują certyfikat G1 przy każdym IKE handshake) 5. Analiza forensic: scope kompromitacji (jakie SA były aktywne z użyciem starego klucza)

35.10. HA, failover i scale-out

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 35.1, 35.3, 34.8

G1 jest single point of entry — jego awaria oznacza brak łączności dla wszystkich operatorów. Dlatego G1 musi być wdrożony w konfiguracji HA (High Availability).

Model HA:

Active-Passive (rekomendowany dla < 5000 operatorów): - Dwa G1: G1-primary i G1-standby - Współdzielony adres IP (VIP) przez VRRP (keepalived) lub cloud floating IP - G1-standby monitoruje G1-primary (healthcheck co 5 sekund) - Failover: < 10 sekund. Routery operatorskie re-establish SA do tego samego IP (DPD detect → restart) - SA state: nie jest synchronizowany między G1 — po failover routery ustanawiają nowe SA (akceptowalny downtime: 10–30 sekund na re-establishment)

Active-Active (rekomendowany dla > 5000 operatorów): - Wiele G1 za load balancerem (L4 — np. HAProxy, cloud NLB, ECMP) - Load balancer: session-sticky per source IP (zapewnia, że ruch od jednego routera trafia do tego samego G1) - Utrata jednego G1: LB przekierowuje ruch na pozostałe, routery re-establish SA - Scale-out: dodawanie kolejnych G1 bez downtime

Disaster Recovery: G1 w drugiej lokalizacji (inny region/DC) z osobnym adresem IP. Router operatorski konfigurowany z dwoma remote_addrs: g1.sylion.example.com (primary) i g1-dr.sylion.example.com (DR). Failover: DNS-based (krótki TTL) lub konfiguracja strongSwan z multiple remotes (IKEv2 supports multiple FQDN resolution).

35.11. Aktualizacje i rebuild G1

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 35.7, 35.10, 49.3

G1 stosuje model immutable infrastructure — aktualizacja oznacza wdrożenie nowej instancji G1 z zaktualizowanym obrazem, nie modyfikację istniejącej.

Procedura aktualizacji: 1. Budowa nowego obrazu G1 (CI/CD) z zaktualizowanymi pakietami (strongSwan, kernel, nftables rules) 2. Testy obrazu w środowisku staging (symulacja tuneli, testy wydajności, testy bezpieczeństwa) 3. Wdrożenie nowego G1 obok istniejącego (blue-green deployment) 4. Przeniesienie ruchu na nowy G1 (LB weight shift lub VIP migration) 5. Monitorowanie nowego G1 przez 24 godziny 6. Po potwierdzeniu stabilności — dezaktywacja starego G1 7. Rollback: przywrócenie ruchu na stary G1 (w ciągu 5 minut)

Rebuild: G1 może być zbudowany od zera w ciągu < 15 minut (provisioning automatyczny: Terraform + Ansible). Rebuild jest wymagany w przypadku: (a) podejrzenia kompromitacji, (b) awarii sprzętowej, (c) aktualizacji krytycznej. Procedura rebuild jest identyczna z procedurą initial deployment — G1 jest stateless.

Okno maintenance: Aktualizacja G1 w trybie HA (35.10) nie wymaga okna maintenance — failover na drugie G1 zapewnia ciągłość. W konfiguracji single G1 — wymagane okno maintenance z powiadomieniem operatorów (planowane: 02:00–04:00 czasu lokalnego, max. 30 minut).

35.12. Monitorowanie integralności

Status: [N] Normatywny Odbiorca: Administrator, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 35.7, 35.8, 46.6

G1 jest komponentem o najwyższym narażeniu — monitoring integralności jest krytyczny.

Mechanizmy: 1. Filesystem integrity monitoring (FIM): Agent (AIDE lub OSSEC) monitoruje hash plików krytycznych: /etc/strongswan.conf, /etc/swanctl/*, /etc/nftables.conf, binaries (/usr/sbin/charon, /usr/sbin/swanctl). Scan co 15 minut. Zmiana → alert CRITICAL 2. Process monitoring: Whitelist procesów (35.7). Nowy proces → alert CRITICAL 3. Network monitoring: Połączenia wychodzące z G1 są ograniczone do Zone 5 (telemetria, logi, NTP). Połączenie do innego adresu → alert CRITICAL 4. Kernel integrity: dm-verity (jeśli immutable rootfs) lub IMA (Integrity Measurement Architecture). Boot z TPM attestation (jeśli hardware to wspiera) 5. Certificate monitoring: Weryfikacja, że certyfikat G1 i CA nie zostały podmienione. Hash certyfikatów porównywany z referencją w Zone 5 co 1 godzinę

Automated response: Alert CRITICAL na G1 uruchamia automatyczną procedurę: 1. Powiadomienie SOC (natychmiast) 2. Snapshot stanu G1 (forensic) 3. Failover na backup G1 (jeśli HA) 4. Izolacja compromised G1 (odcięcie od sieci) 5. Rebuild G1 (35.11) po analizie forensic

35.13. Procedury awaryjne G1

Status: [N] Normatywny Odbiorca: Administrator, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 35.10, 35.12, 50.1

Procedury awaryjne G1 obejmują scenariusze utraty lub kompromitacji bramy:

Scenariusz 1: Awaria sprzętowa / crash G1 1. Automatyczny failover na G1-standby (HA) — czas: < 10 sekund 2. Routery operatorskie: DPD timeout → restart → ustanowienie nowej SA do VIP 3. SOC: alert i weryfikacja przyczyny awarii 4. Rebuild uszkodzonego G1 → powrót do konfiguracji HA

Scenariusz 2: Podejrzanie kompromitacji G1 1. SOC potwierdza alert integrity (35.12) 2. Natychmiastowe odcięcie G1 od sieci (firewall rule lub fizyczne odłączenie) 3. Failover na G1-standby (jeśli HA) lub G1-DR 4. Unieważnienie certyfikatu G1 i klucza prywatnego 5. Snapshot G1 do forensic 6. Rebuild G1 z nowym kluczem i certyfikatem 7. Ocena scope: czy napastnik mógł przechwycić ruch? (ESP jest szyfrowany AEAD — przechwycenie jest mało prawdopodobne bez klucza prywatnego, chyba że kompromitacja dotyczy klucza) 8. Powiadomienie operatorów (jeśli wymagane)

Scenariusz 3: Atak DDoS na G1 1. Automatyczne skalowanie ochrony (cloud scrubbing, flowspec) 2. Aktywacja dodatkowych reguł rate limiting (35.5) 3. Jeśli atak przekracza pojemność ochrony — failover na G1-DR (inny adres IP) 4. Powiadomienie ISP / cloud provider 5. Post-incident: analiza wektorów ataku, aktualizacja reguł

Scenariusz 4: Utrata łączności wszystkich operatorów (global outage) 1. Weryfikacja: G1, ISP, DNS, infrastruktura chmurowa 2. Status page: aktualizacja z informacją dla operatorów 3. Eskalacja do cloud provider (jeśli problem po stronie DC) 4. Komunikacja z operatorami przez alternatywny kanał (email, SMS, Matrix federacyjny jeśli dostępny) 5. Post-incident: RCA (Root Cause Analysis), aktualizacja procedur

Każdy scenariusz ma dedykowany playbook w rejestrze playbooków (50.9) z precyzyjnymi krokami, rolami i SLA czasowymi.

Rozdział 36. G2 — Access Broker i warstwa polityk

36.1. Rola G2 w architekturze

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 35.1, 37.1, 44.1

G2 (Access Broker) jest centralnym punktem decyzyjnym platformy SYLION — odpowiada za autoryzację dostępu operatora do środowisk roboczych. Rezyduje w Zone 2 (strefa bram), za G1, i stanowi logiczną bramę między warstwą transportową a warstwą aplikacyjną.

W modelu Split Gateway architektura rozdziela odpowiedzialność: - G1 = „Czy pakiet jest ważny?” (warstwa sieciowa, uwierzytelnienie tunelu) - G2 = „Czy operator ma prawo dostępu?” (warstwa polityk, autoryzacja sesji)

G2 podejmuje decyzje na podstawie: 1. Tożsamość operatora — weryfikacja tokenu OIDC/SAML, stan konta w IAM (44.1) 2. Device posture — raport zgodności terminala z MDM (32.14): szyfrowanie, aktualizacje, FIDO2 3. Polityka dostępu — reguły OPA/Rego (45.3) definiujące, który operator ma dostęp do jakich workloadów 4. Kontekst — czas, lokalizacja (geofencing), ryzyko (risk score z SIEM), tier operatora 5. Stan środowiska — czy workload docelowy jest dostępny, czy operator ma aktywne inne sesje

Decyzja G2 jest binarna: ALLOW (operator jest przekierowany do Session Broker) lub DENY (operator widzi komunikat z przyczyną odmowy i instrukcją naprawczą).

G2 jest komponentem stanowym — utrzymuje bazę aktywnych sesji, cache polityk, cache device posture. Jednakże stan jest rekonstruowalny z systemów źródłowych (IAM, MDM, OPA) — utrata G2 nie oznacza utraty danych, a jedynie konieczność ponownego uwierzytelnienia operatorów.

G2 nie widzi treści sesji — po autoryzacji ruch streamingowy (piksele, audio) przechodzi bezpośrednio z Session Broker do operatora, bez pośrednictwa G2. G2 kontroluje wyłącznie moment wejścia (admission) i okresowe re-weryfikacje (periodic policy check).

36.2. Model autoryzacji

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.1, 44.5, 45.1

G2 implementuje model autoryzacji oparty na połączeniu RBAC (Role-Based Access Control), ABAC (Attribute-Based Access Control) i PBAC (Policy-Based Access Control):

RBAC: Operator ma przypisaną rolę (np. operator-standard, operator-pro, admin-tier1) definiującą bazowy zestaw dostępnych workloadów.

ABAC: Atrybuty operatora (tier, lokalizacja, czas, device posture) modyfikują decyzję bazową. Np. operator z rolą operator-pro z niezgodnym terminalem (brak aktualizacji) jest odrzucany mimo posiadania roli.

PBAC: Silnik polityk OPA/Rego (45.3) ewaluje złożone reguły kontekstowe. Np.:

```
allow { input.operator.role == "operator-pro" input.device.compliant == true input.device.encryption == true input.time.hour >= 6 input.time.hour <= 22
input.risk_score < 70 }
```

Przepływ autoryzacji: 1. Operator ustanawia tunel IPsec (G1 → uwierzytelnienie certyfikatem) 2. Operator żąda sesji (HTTPS do G2) 3. G2 weryfikuje token OIDC (wystawiony przez IdP SYLION — 44.10) 4. G2 pobiera device posture z MDM (32.14) 5. G2 ewaluje politykę OPA/Rego z pełnym kontekstem 6. ALLOW → G2 wystawia session admission token i przekierowuje do Session Broker 7. DENY → G2 zwraca komunikat z kodem odmowy i instrukcją

Least privilege: Operator otrzymuje dostęp wyłącznie do workloadów jawnie dozwolonych przez politykę. Domyślnie: brak dostępu (default deny).

36.3. Mapowanie operator → środowisko

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 36.2, 38.1, 38.2

Każdy operator w SYLION ma przypisany zestaw środowisk (workloadów), do których może uzyskać dostęp. Mapowanie jest przechowywane w bazie konfiguracyjnej G2 i zarządzane przez administratora.

Standardowe mapowanie (per tier):

Workload	STANDARD	PRO	STATE
env-matrix	✓	✓	✓
env-signal	X	✓	✓
env-browser	✓	✓	✓
env-office	✓	✓	✓
env-crm	X	✓	✓
env-voice	X	✓	✓
env-custom-*	X	Opcjonalne	✓

Mapowanie jest konfigurowane per operator — administrator może dodawać lub usuwać workloady dla konkretnego operatora, niezależnie od domyślnego mapowania tieru.

Dynamiczne mapowanie: W zaawansowanych scenariuszach mapowanie może być dynamiczne — np. operator uzyskuje dostęp do env-crm wyłącznie w godzinach pracy (8:00–18:00), lub env-custom-finance jest dostępny wyłącznie operatorom z atrybutem department=finance. Logika dynamicznego mapowania jest realizowana przez polityki OPA/Rego (Rozdział 45).

Zmiana mapowania: Każda zmiana mapowania jest procesem change management (46.8): (a) wniosek z uzasadnieniem, (b) zatwierdzenie przez uprawnionego administratora, (c) wdrożenie zmiany w konfiguracji G2, (d) audyt trail. Dla tieru STATE zmiana mapowania wymaga dual authorization (46.10).

36.4. Kontrola admisyj sesji (Session Admission Control)

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.2, 37.1, 32.11

Session admission control to proces decyzyjny G2 wykonywany przy każdym żądaniu sesji operatora. Proces ten jest bramą wejściową — bez pozytywnej decyzji G2 operator nie uzyska sesji streamingowej.

Dane wejściowe do decyzji:

Źródło	Dane	Sprawdzenie
Token OIDC	Tożsamość, rola, tenant, tier	Podpis, ważność, issuer, audience
MDM	Device posture	Compliance status, timestamp raportu
Asset Inventory	Device ID, status	Czy terminal jest zarejestrowany i aktywny
FIDO2	Ostatnia weryfikacja	Czy FIDO2 challenge został ukończony < X minut temu
SIEM	Risk score	Czy nie ma aktywnego alertu dla tego operatora
G2 state	Active sessions	Czy operator nie ma już aktywnej sesji (limit per operator)
Policy engine	Wynik ewaluacji	ALLOW / DENY

Limit sesji: Domyślnie operator może mieć jedną aktywną sesję. Dla tieru PRO/STATE dopuszczalne są dwie jednoczesne sesje (np. Pixel + laptop). Trzecia próba → DENY z komunikatem „Limit sesji osiągnięty.”

Freshness: Device posture report musi być świeży: max. 5 minut od ostatniego heartbeat. Starszy raport → DENY z komunikatem „Raport zgodności terminala nieaktualny — oczekiwanie na heartbeat.”

Re-admission: Po zamknięciu sesji (timeout, re-auth failure, manual disconnect) operator musi ponownie przejść pełną kontrolę admisyj. Nie istnieje mechanizm „wznowienia sesji” bez ponownej weryfikacji.

36.5. Device posture i atrybuty urządzeń

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 32.14, 36.4, 45.8

Device posture to raport o stanie terminala, generowany przez agenta MDM i przekazywany do G2. Raport stanowi kluczowy element decyzji admisyj sesji.

Atrybuty device posture:

Atrybut	Typ	Wymagany	Opis
device_id	string	Tak	Unikalny identyfikator terminala
compliant	boolean	Tak	Ogólny status zgodności z baseline
encryption_enabled	boolean	Tak	Czy szyfrowanie dysku jest aktywne
os_version	string	Tak	Wersja systemu operacyjnego
os_patch_level	date	Tak	Data ostatniej łatki bezpieczeństwa
mdm_enrolled	boolean	Tak	Czy terminal jest zarządzany przez MDM

fido2_paired	boolean	Tak	Czy klucz FIDO2 jest sparowany
screen_lock_enabled	boolean	Tak	Czy blokada ekranu jest aktywna
usb_debug_disabled	boolean	Tak	Czy USB debug jest wyłączony
developer_mode_disabled	boolean	Tak	Czy tryb deweloperski jest wyłączony
last_heartbeat	timestamp	Tak	Timestamp ostatniego heartbeat
firewall_enabled	boolean	Dla desktopów	Czy firewall hosta jest aktywny
secure_boot	boolean	Tak	Czy Secure Boot / Verified Boot jest aktywny
geo_location	coordinates	STATE	Przybliżona lokalizacja (geofencing)

Format: Device posture jest przekazywany jako JSON Web Token (JWT) podpisany przez system MDM. G2 weryfikuje podpis JWT, sprawdza ważność (timestamp) i ewaluje atrybuty w kontekście polityki.

Logika: G2 porównuje atrybuty z wymaganiami baseline dla danego tieru (32.14). Brak spełnienia wymaganego atrybutu → DENY. Brak spełnienia rekomendowanego atrybutu → ALLOW + warning w logach.

36.6. Egzekwowanie polityk

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.2, 45.1, 45.6

G2 egzekwuje polityki zdefiniowane w silniku OPA/Rego (Rozdział 45). Egzekwowanie odbywa się na trzech poziomach:

Poziom 1 — Admisja (pre-session): Polityki weryfikowane przed przyznaniem sesji: tożsamość, device posture, czas, lokalizacja, risk score. Wynik: ALLOW/DENY.

Poziom 2 — Ciągła weryfikacja (in-session): G2 periodycznie (co 5 minut) re-ewaluje politykę dla aktywnych sesji. Jeśli warunki zmieniły się (np. device posture stał się non-compliant, risk score wzrósł powyżej progu, minął dozwolony czas) — G2 wysyła do Session Broker polecenie zamknięcia sesji. Operator widzi komunikat z przyczyną.

Poziom 3 — Decyzje eksportowe (per-action): G2 jest konsultowany przy próbie eksportu danych z workloadu (42.7): transfer pliku, kopiowanie do schowka, drukowanie, screen capture. Każda taka operacja wymaga osobnej decyzji G2 na podstawie export policy (45.7).

Cache polityk: G2 cachuje wynik ewaluacji polityki (TTL: 60 sekund) aby nie obciążać silnika OPA przy każdym żądaniu. Cache jest invalidowany natychmiast przy: zmianie polityki, zmianie device posture, zmianie risk score.

Audit: Każda decyzja G2 jest logowana: operator ID, device ID, wynik (ALLOW/DENY), przyczyna, timestamp, policy version. Logi są niemodyfikowalne (append-only) i przechowywane w SIEM (46.6).

36.7. Broker decyzji eksportowych (Export Decision Broker)

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.6, 42.1, 45.7

G2 pełni rolę brokera decyzji eksportowych — każda operacja wynosząca dane z Zone 3 (środowisko operatora) wymaga autoryzacji G2.

Operacje eksportowe wymagające decyzji: 1. Transfer pliku na terminal — operator chce pobrać plik z workloadu na swój terminal 2. Clipboard copy — operator chce skopiować treść ze schowka workloadu do schowka terminala 3. Drukowanie — operator chce wydrukować dokument z workloadu 4. Screen capture — operator próbuje przechwycić obraz ekranu workloadu 5. Email/chat z załącznikiem — operator chce wysłać plik z workloadu przez email lub komunikator do adresata zewnętrznego

Przepływ: 1. Session Broker przechwytuje operację eksportową 2. Session Broker wysyła request do G2: {operator, device, workload, action, metadata} 3. G2 ewaluje export policy (45.7) 4. ALLOW → Session Broker przepuszcza operację (plik przechodzi przez CDR pipeline — 42.6) 5. DENY → Operator widzi komunikat „Operacja zablokowana przez politykę bezpieczeństwa” 6. AUDIT → Decyzja logowana niezależnie od wyniku

Polityki eksportowe domyślne: | Operacja | STANDARD | PRO | STATE | |—|—|—| | File download to terminal | Zablokowany | Dozwolony (po CDR) | Zablokowany (wyjątki per operator) | | Clipboard copy out | Zablokowany | Dozwolony (tekst, max 4 KB) | Zablokowany | | Print | Zablokowany | Dozwolony (logowany) | Wymagana dual auth | | Screen capture | Zablokowany | Zablokowany | Zablokowany | | External email attachment | Zablokowany | Dozwolony (po CDR + DLP) | Wymagana dual auth |

Administrator może modyfikować polityki eksportowe per operator, per workload, per tier. Każda modyfikacja wymaga change management.

36.8. Staging plików

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 36.7, 42.1, 42.6

Pliki eksportowane z workloadu nie są bezpośrednio transferowane na terminal — przechodzą przez staging area kontrolowany przez G2.

Pipeline staging: 1. Operator inicjuje eksport pliku z workloadu 2. Session Broker przekazuje plik do staging area (tymczasowy storage w Zone 2) 3. G2 weryfikuje decyzję eksportową (36.7) 4. Plik przechodzi pipeline CDR (Content Disarm and Reconstruction — 42.6): walidacja typu, skanowanie malware, stripping metadanych, rekonstrukcja 5. Plik po CDR jest umieszczany w staging area „clean” 6. Session Broker dostarcza plik na terminal operatora 7. Plik w staging area jest usuwany po 15 minutach lub po potwierdzeniu dostarczenia

Staging area: - Izolowany storage (wolumen lub bucket) w Zone 2 - Szyfrowany at-rest (AES-256) - Retention: max. 1 godzina (automatyczne czyszczenie) - Brak dostępu z innych workloadów — wyłącznie G2 i CDR pipeline - Monitoring: alert przy nietypowym wolumenie plików (exfiltration detection)

Pliki wchodzące do Zone 3 (upload z terminala do workloadu) przechodzą analogiczny pipeline — CDR na wejściu jest obowiązkowy dla wszystkich plików (42.1).

36.9. Routing workloadów

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 36.3, 37.1, 38.1

G2 decyduje, do którego workloadu (środowiska) operator zostanie skierowany. Routing obejmuje:

Selekcja workloadu: Operator żąda dostępu do konkretnego workloadu (np. env-matrix). G2 weryfikuje: (a) czy operator ma mapowanie do tego workloadu (36.3), (b) czy workload jest dostępny (healthcheck), (c) czy polityka dopuszcza dostęp w danym kontekście.

Lokalizacja workloadu: Workloady operatora mogą rezydować na różnych hostach fizycznych (w ramach orkiestracji — 38.1). G2 utrzymuje mapę operator → host → workload i kieruje żądanie do odpowiedniej instancji Session Broker.

Load balancing: Jeśli istnieje wiele instancji Session Broker, G2 wybiera instancję na podstawie: obciążenia (least connections), lokalizacji (proximity), stanu zdrowia (healthcheck).

Failover workloadu: Jeśli workload jest niedostępny (crash, maintenance), G2: (a) informuje operatora o niedostępności, (b) próbuje uruchomić odbudowę workloadu (38.11), (c) po odbudowie — automatycznie przyznaje sesję.

36.10. Logowanie i audyt G2

Status: [N] Normatywny Odbiorca: Administrator, Audytor, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.6, 46.6, 46.12

G2 generuje kompletny audyt trail obejmujący wszystkie decyzje i zdarzenia:

Zdarzenia logowane: | Zdarzenie | Poziom | Dane | |—|—| | Session admission ALLOW | INFO | operator_id, device_id, workload, policy_version, timestamp | | Session admission DENY | WARN | operator_id, device_id, deny_reason, policy_version, timestamp | | Export decision ALLOW | INFO | operator_id, action, file_metadata, policy_version | | Export decision DENY | WARN | operator_id, action, deny_reason, policy_version | | Session terminated (policy) | WARN | operator_id, reason (policy change, device non-compliant) | | Session terminated (timeout) | INFO | operator_id, duration | | Session terminated (operator) | INFO | operator_id, duration | | Policy update loaded | INFO | policy_version, hash, admin_id | | Device posture change | INFO | device_id, old_status, new_status | | G2 healthcheck failure | ERROR | component, details |

Format: JSON structured log, wysyłany przez mTLS do SIEM w Zone 5.

Retention: Logi G2 są przechowywane: 1 rok (STANDARD/PRO), 5 lat (STATE). Logi nie mogą być modyfikowane ani usuwane — append-only log z integralności chain (hash łańcuchowy).

Compliance: Logi G2 stanowią dowód audytowy dla regulatorów. W przypadku audytu zewnętrznego — logi są udostępniane w formacie eksportowym (CSV/JSON) z weryfikowalnym łańcuchem integralności.

36.11. HA, failover i rebuild G2

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 36.1, 35.10, 46.1

G2 jest komponentem krytycznym — jego awaria uniemożliwia nowym operatorom uzyskanie sesji. Aktywne sesje kontynuują (Session Broker działa niezależnie), ale nowe admisyje i re-admisyje po timeout są zablokowane.

Model HA: - Active-Passive z shared state (baza aktywnych sesji w Redis/PostgreSQL HA) - Failover: < 15 sekund (healthcheck + VIP migration) - State synchronization: baza sesji jest replikowana synchronicznie między G2-primary i G2-standby

Rebuild: G2 jest rebuildowalny od zera w < 10 minut (Terraform + Ansible): 1. Provisioning VM/kontenera 2. Instalacja komponentów (Envoy/nginx proxy, OPA sidecar, Redis/PostgreSQL client) 3. Konfiguracja z repozytorium (Git) 4. Podłączenie do systemów źródłowych (IAM, MDM, SIEM) 5. Załadowanie polityk z OPA bundle 6. Healthcheck → dodanie do LB/VIP

Graceful degradation: Jeśli G2 jest niedostępny, a operator ma aktywną sesję z ważnym tokenem — Session Broker kontynuuje sesję do wygaśnięcia tokena (max. 1 godzina). Po wygaśnięciu — sesja jest zamykana. Operator musi poczekać na przywrócenie G2.

36.12. Ochrona integralności i regresja polityk

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.6, 45.13, 46.8

Integralność G2 jest krytyczna — kompromitacja G2 oznacza potencjalne ominięcie kontroli dostępu.

Ochrona integralności: - Immutable infrastructure: G2 działa na immutable OS image (jak G1) - FIM (File Integrity Monitoring) na binarnych i konfiguracjach - Policy integrity: polityki OPA/Rego są podpisywane (Ed25519) w pipeline CI/CD. G2 weryfikuje podpis przed załadowaniem. Niezgodny podpis → odmowa załadowania + alert CRITICAL - API G2 jest dostępne wyłącznie z Zone 2 inner network — brak dostępu z internetu

Regresja polityk (Policy regression): Zmiana polityki, która osłabia bezpieczeństwo (np. usunięcie wymagania FIDO2) jest wykrywana przez mechanizm policy diff: 1. Przy każdej zmianie polityki — automatyczne porównanie z poprzednią wersją 2. Detekcja zmian osłabiających (regression): usunięcie warunków, dodanie wyjątków, zmiana DENY → ALLOW 3. Zmiana osłabiająca wymaga explicit approval (dual authorization dla STATE) 4. Logi: kto zmienił, co zmienił, kto zatwierdził

36.13. Procedury awaryjne G2

Status: [N] Normatywny Odbiorca: Administrator, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.11, 35.13, 50.1

Scenariusz 1: Awaria G2 1. Failover na G2-standby (HA — 36.11) 2. Aktywne sesje kontynuują (Session Broker niezależny) 3. Nowe sesje: oczekiwanie na przywrócenie G2 4. SOC: alert, diagnoza przyczyny 5. Rebuild G2 → przywrócenie HA

Scenariusz 2: Podejrzanie kompromitacji G2 1. SOC potwierdza alert integrality 2. Natychmiastowa izolacja G2 od sieci 3. Zamknięcie wszystkich aktywnych sesji (Session Broker: terminate all) 4. Snapshot G2 do forensics 5. Rebuild G2 od zera z czystego image 6. Re-enrollment operatorów (opcjonalnie — zależy od scope kompromitacji) 7. Przegląd logów: czy nieautoryzowane sesje zostały przyznane?

Scenariusz 3: Policy engine failure (OPA down) 1. G2 przechodzi w tryb fail-close: wszystkie nowe sesje DENY 2. Aktywne sesje: kontynuują do wygaśnięcia tokena 3. SOC: restart OPA, weryfikacja integralności polityk 4. Po przywróceniu OPA: normalne działanie

Fail-close jest domyślnym zachowaniem G2 — w razie wątpliwości G2 odmawia dostępu. Fail-open jest niedopuszczalny w żadnym tierze.

Rozdział 37. Session Broker i streaming obrazu

37.1. Rola Session Broker

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.1, 38.1, 41.1

Session Broker jest komponentem odpowiedzialnym za ustanowienie, utrzymanie i terminowanie sesji streamingowej między terminalem operatora a jego środowiskiem roboczym (workload) w Zone 3. Broker jest realizacją modelu Thin Client — przekształca obraz pulpitu workloadu w strumień pikseli i dźwięku, transmitowany do terminala.

Kluczowe funkcje: 1. Ustanowienie sesji streamingowej po autoryzacji przez G2 2. Renderowanie i kompresja obrazu pulpitu workloadu (screen capture → encode → stream) 3. Transport strumienia pikseli do terminala (media plane) 4. Transport inputu od terminala do workloadu (klawiatura, mysz, dotyk) 5. Transport audio (terminal → workload) 6. Egzekwowanie polityk sesji: clipboard, file redirect, print, screen capture (na polecenie G2) 7. Zarządzanie tokenami sesji (krótkotrwałe, odnawialne) 8. Monitoring jakości sesji (latencja, FPS, bitrate)

Session Broker rezyduje w Zone 3 (blisko workloadów operatorów) — minimalizacja latencji między brokerem a workloadem. Ruch z terminala dociera do brokera przez tunel IPsec → G1 → Zone 2 inner → Session Broker w Zone 3.

Model Session Broker jest inspirowany rozwiązaniami: Apache Guacamole (open source), Citrix HDX, VMware Blast Extreme, oraz Hypori (encrypted pixel streaming dla urządzeń mobilnych). SYLION preferuje podejście typu Hypori — strumień pikseli jest szyfrowany end-to-end (TLS 1.3 lub SFrame), a terminal nie ma możliwości lokalnego przetwarzania danych z workloadu.

37.2. App-only publishing

Status: [R] Rekomendowany Odbiorca: Administrator, Architekt Wpływ na baseline: Średni Powiązane rozdziały: 37.1, 37.3, 38.1

App-only publishing oznacza publikację pojedynczej aplikacji — operator widzi na terminalu wyłącznie okno konkretnej aplikacji (np. przeglądarka, klient Matrix, edytor dokumentów), a nie cały pulpit systemu operacyjnego workloadu.

Zalety: - Mniejsza powierzchnia ataku — operator nie ma dostępu do powłoki systemowej ani innych aplikacji workloadu - Lepsze doświadczenie użytkownika na terminalu mobilnym — okno aplikacji jest zoptymalizowane pod ekran dotykowy - Możliwość publikacji wielu aplikacji z różnych workloadów jednocześnie (operator widzi kilka okien z różnych środowisk)

Implementacja: Session Broker przechwytuje obraz konkretnego okna aplikacji (Xorg / Wayland window capture) zamiast całego pulpitu. Na terminalu okno jest renderowane jako oddzielna powierzchnia (na Androidzie: osobne Activity; na desktopie: oddzielne okno).

Ograniczenia: - Nie wszystkie aplikacje dobrze działają w trybie app-only (np. aplikacje z wieloma oknami, dialogi modalne) - Wymaga integracji z window manager workloadu - Notifications/toasts mogą być niewidoczne

App-only publishing jest rekomendowany jako domyślny tryb dla env-matrix, env-browser, env-office. Full desktop (37.3) jest preferowany dla env-crm i env-custom (złożone aplikacje).

37.3. Limited workspace

Status: [R] Rekomendowany Odbiorca: Administrator, Architekt Wpływ na baseline: Średni Powiązane rozdziały: 37.2, 37.4, 38.1

Limited workspace to tryb pośredni między app-only publishing a full desktop. Operator widzi uproszczony pulpit z ograniczonym zestawem elementów: (a) pasek zadań z opublikowanymi aplikacjami, (b) menedżer plików ograniczony do katalogu roboczego, (c) brak dostępu do terminala/powłoki, (d) brak możliwości instalacji oprogramowania.

Implementacja: Workload uruchamia dedykowany window manager (np. Openbox z customową konfiguracją) z zablokowanym menu kontekstowym, zablokowanym dostępem do terminala i ograniczoną listą aplikacji w menu.

Zalety: - Operator może pracować z wieloma aplikacjami jednocześnie (drag & drop, kopiowanie między oknami) - Mniejsza złożoność niż full desktop — mniej elementów do zarządzania - Lepsze bezpieczeństwo niż full desktop — brak powłoki systemowej

Limited workspace jest rekomendowany dla tieru STANDARD (ogranicza ekspozycję) i jako domyślny tryb dla tieru PRO.

37.4. Full desktop publishing

Status: [O] Opcjonalny Odbiorca: Administrator, Architekt Wpływ na baseline: Niski Powiązane rozdziały: 37.2, 37.3, 38.1

Full desktop publishing udostępnia operatorowi pełny pulpit systemu operacyjnego workloadu — ze standardowym środowiskiem graficznym (GNOME, KDE, XFCE lub Windows Desktop).

Zakres: Operator widzi kompletny desktop workloadu i może korzystać ze wszystkich zainstalowanych aplikacji, menedżera plików, ustawień systemowych. Dostęp do terminala/powłoki może być dozwolony lub zablokowany (polityka).

Użycie: Full desktop jest przeznaczony dla: (a) operatorów wymagających pełnej elastyczności (analitycy, deweloperzy), (b) workloadów z kompleksowymi aplikacjami (env-crm z wieloma modułami), (c) tieru STATE z dedykowanymi środowiskami.

Ryzyko: Full desktop zwiększa powierzchnię ataku — operator z dostępem do powłoki może próbować eskalować uprawnienia, eksfiltrować dane lub modyfikować konfigurację workloadu. Dlatego: (a) workload działa z ograniczonymi uprawnieniami (non-root, seccomp, AppArmor — 38.8), (b) egress jest kontrolowany (38.9), (c) audit trail na poziomie workloadu (38.14).

37.5. Transport obrazu (protokoły)

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 37.1, 37.17, 41.7

Session Broker musi transmitować obraz pulpitu workloadu do terminala z niską latencją i wystarczającą jakością. Wybór protokołu transportu obrazu jest kluczową decyzją architektoniczną.

Opcje protokołu:

Protokół	Zalety	Wady	Ocena SYLION
RDP (Remote Desktop Protocol)	Dojrzały, szeroko wspierany, dobrze zoptymalizowany	Proprietary (Microsoft), złożony, historyczne podatności	Opcjonalny (interop)
VNC (RFB)	Otwarty, prosty	Wysoka latencja, brak kompresji H.264, brak audio	Nie rekomendowany
SPICE	Otwarty (Red Hat), dobra jakość, obsługa USB/audio	Głównie Linux, ograniczone wsparcie klienta mobilnego	Rekomendowany (Linux)
Apache Guacamole (HTML5 + RDP/VNC)	Clientless (przeglądarka), open source	Dodatkowa warstwa (proxy), latencja	Opcjonalny (fallback)
Custom pixel stream (H.264/VP9/AV1 over WebRTC)	Najniższa latencja, najlepsza kontrola, szyfrowanie E2E	Złożoność implementacji	Preferowany

Preferowane rozwiązanie: SYLION preferuje custom pixel streaming oparty na: - Capture: framebuffer capture z workloadu (DRM/KMS na Linuksie, DXGI na Windows) - Encode: sprzętowy enkoder H.264/H.265 (VA-API, NVENC) lub programowy (x264/SVT-AV1) - Transport: WebRTC DataChannel (DTLS-SRTP) lub dedykowany protokół UDP z FEC (Forward Error Correction) - Decode: sprzętowy dekodery na terminalu (MediaCodec na Androidzie, VideoToolbox na macOS)

Latencja end-to-end (glass-to-glass): < 50 ms (cel), < 100 ms (akceptowalna), > 150 ms (degradacja doświadczenia). Bitrate: 5–20 Mbps (adaptacyjny, zależny od rozdzielczości i zmienności obrazu). FPS: 30 (standard), 60 (rekomendowany dla interaktywnego użycia).

37.6. Transport inputu

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 37.1, 37.5, 37.9

Transport inputu obejmuje przesyłanie zdarzeń klawiatury, myszy i dotykowych z terminala do workloadu.

Wymagania: - Latencja input → display: < 100 ms (klawiatura) — operator nie powinien odczuwać opóźnienia między naciśnięciem klawisza a wyświetleniem znaku - Latencja input → display: < 50 ms (mysz/cursor) — odpowiedź wizualna kursora musi być natychmiastowa - Niezawodność: żadne zdarzenie input nie może być utracone — TCP-like reliability na warstwie inputu (retransmisja) - Bezpieczeństwo: input jest szyfrowany (w ramach sesji TLS/DTLS)

Architektura: Input jest transportowany osobnym kanałem (control channel) od strumienia pikseli (media channel). Control channel: TCP/TLS lub WebRTC DataChannel (reliable mode). Media channel: UDP/DTLS (unreliable — utrata pojedynczego frame jest akceptowalna).

Separacja kanałów zapewnia, że opóźnienie w media channel (np. buforowanie video) nie wpływa na latencję inputu, i odwrotnie — duża ilość inputu nie blokuje strumienia video.

Input validation: Session Broker waliduje zdarzenia input przed przekazaniem do workloadu: - Rate limiting: max. 1000 zdarzeń/sekundę per operator (ochrona przed flood) - Sanitization: odrzucenie zdarzeń o nieprawidłowym formacie - Keylogging protection: Session Broker nie loguje treści inputu (klawisze) — logowane są wyłącznie metadane (timestamp, typ zdarzenia, source)

37.7. Transport audio terminala

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 37.1, 41.1, 41.7

Audio jest transportowane dwukierunkowo: (a) audio z workloadu → terminal (odsluch), (b) audio z terminala → workload (mikrofon).

Architektura: Audio jest częścią media plane sesji streamingowej. Kodek: Opus (RFC 6716) — najlepsza jakość przy niskim bitrate, obsługa mowy i muzyki, adaptacyjny bitrate.

Parametry: | Parametr | Wartość | |---| | Kodek | Opus | | Sample rate | 48 kHz | | Bitrate | 24–128 kbps (adaptacyjny) | | Frame size | 20 ms | | Kanały | Mono (voice), Stereo (media) | | Latencja | < 100 ms (E2E, audio-only) |

Kierunek audio: - Workload → Terminal: Audio z aplikacji workloadu (np. dzwonek Matrix, dźwięk wideo, muzyka z przeglądarki) jest przechwytywane z PulseAudio/PipeWire workloadu, enkodowane Opus i transmitowane w media channel - Terminal → Workload: Mikrofon terminala jest przechwytywany przez klienta sesji, enkodowany Opus i transmitowany do workloadu. W workloadzie audio z mikrofonu jest dostępne jako wirtualne urządzenie wejściowe (PulseAudio module)

Polityki audio: - Mikrofon terminala: domyślnie wyłączony, aktywowany na żądanie operatora (per sesja) - Audio z workloadu: domyślnie włączone - Nagrywanie audio: zablokowane na poziomie Session Broker (operator nie może nagrywać audio sesji)

37.8. Tokeny sesji krótkotrwałe

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.4, 37.1, 44.12

Sesja streamingowa jest autoryzowana tokenem wystawionym przez G2. Token jest krótkotrwały, niesymetryczny i jednorazowy.

Właściwości tokena sesji: - Format: JWT (JSON Web Token) podpisany kluczem Ed25519 G2 - Czas życia: 15 minut (nowy token), odnawiany co 10 minut - Claims: operator_id, device_id, workload_id, session_id, tier, issued_at, expires_at, scopes (dozwolone operacje) - Jednorazowość: token może być użyty do ustanowienia jednej sesji. Po użyciu jest unieważniany (nonce tracking) - Binding: token jest powiązany z Device ID i adresem IP tunelu — użycie z innego urządzenia/IP → odmowa

Odnawianie: Session Broker periodycznie żąda nowego tokenu od G2 (co 10 minut). G2 re-ewaluuje politykę (36.6 — ciągła weryfikacja) i wystawia nowy token lub odmawia (sesja terminowana).

Kompromitacja tokenu: Krótki czas życia (15 minut) i binding do device/IP ograniczają window of opportunity. Nawet przechwycony token jest bezużyteczny bez kontroli nad terminalem operatora (tunel IPsec + device binding).

37.9. Polityki schowka (Clipboard)

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 36.7, 37.1, 42.1

Schowek (clipboard) jest potencjalnym kanałem eksfiltracji danych — kopiowanie treści z workloadu do schowka terminala omija pipeline CDR. Dlatego polityki schowka są ściśle kontrolowane.

Kierunki: - Workload → Terminal (copy out): Kopiowanie treści z workloadu do schowka terminala - Terminal → Workload (paste in): Wklejanie treści z terminala do workloadu - Workload → Workload (cross-workload): Kopiowanie między workloadami tego samego operatora

Polityki domyślne:

Kierunek	STANDARD	PRO	STATE
Copy out (workload → terminal)	Zablokowany	Tekst, max 4 KB	Zablokowany
Paste in (terminal → workload)	Dozwolony	Dozwolony	Tekst, max 4 KB
Cross-workload	Zablokowany	Dozwolony (ten sam tier)	Wymagana polityka

Implementacja: Session Broker przechwytuje operacje schowka na granicy terminal ↔ workload. Schowek nie jest współdzielony — Session Broker działa jako proxy schowka, ewaluując politykę G2 przy każdej operacji.

Logowanie: Każda operacja schowka jest logowana: timestamp, operator, kierunek, typ treści (text/image/file), rozmiar. Treść schowka NIE jest logowana (privacy) — chyba że polityka DLP wymaga inspekcji treści.

37.10. Polityki przekierowania plików (File Redirect)

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 36.7, 42.1, 37.9

File redirect umożliwia mapowanie zasobu dyskowego terminala (np. folderu Downloads) do workloadu — pliki z terminala są widoczne w workloadzie i odwrotnie. W SYLION file redirect jest domyślnie WYŁĄCZONY dla wszystkich tierów. Jest to celowa decyzja — file redirect omija pipeline CDR i stanowi bezpośredni kanał eksfiltracji/infiltracji.

Wyjątek: Kontrolowany transfer plików przez staging area (36.8) z obowiązkowym pipeline CDR (42.6). Operator nie widzi plików terminala w workloadzie — zamiast tego korzysta z dedykowanego interfejsu upload/download z CDR.

Jeśli organizacja wymaga file redirect (scenariusz legacy), wymaga to: (a) jawnej akceptacji ryzyka przez CISO, (b) ograniczenia do konkretnych katalogów i typów plików, (c) skanowania w czasie rzeczywistym (real-time AV + CDR), (d) pełnego audytu. Dla tieru STATE file redirect jest bezwzględnie niedopuszczalny.

37.11. Polityki drukowania (Print)

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Średni Powiązane rozdziały: 36.7, 37.1, 42.14

Drukowanie z workloadu na drukarce fizycznej podłączonej do sieci terminala jest potencjalnym kanałem eksfiltracji.

Polityki domyślne: | Tier | Drukowanie | |—| | STANDARD | Zablokowane | | PRO | Dozwolone (logowane, CDR na dokumencie przed drukowaniem) | | STATE | Wymagana dual authorization per zlecenie druku |

Implementacja: Drukowanie w workloadzie jest przechwytywane przez wirtualny sterownik drukarki. Dokument (PDF/PostScript) jest: (a) przekazywany do G2 (decyzja eksportowa), (b) poddawany CDR (usunięcie metadanych, watermarking z operator_id i timestamp), (c) przekazywany do terminala (Session Broker), (d) drukowany na drukarce lokalnej terminala (jeśli dostępna i dozwolona).

Watermarking: Dla tieru PRO/STATE wydrukowane dokumenty zawierają niewidoczny watermark (steganografia) z: operator_id, timestamp, workload_id. Umożliwia to identyfikację źródła w przypadku wycieku dokumentu fizycznego.

37.12. Polityki przechwytywania ekranu (Screen Capture)

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 36.7, 37.1, 32.3

Screen capture (zrzut ekranu, nagrywanie ekranu) jest najłatwiejszym kanałem eksfiltracji — operator może zrobić zrzut ekranu terminala wyświetlającego dane z workloadu.

Ochrona wielowarstwowa:

Warstwa 1 — Polityka Session Broker: Session Broker oznacza strumień pikseli flagą DRM/secure (Android: FLAG_SECURE, macOS: screen capture prevention API). Na terminalu mobilnym (Pixel) FLAG_SECURE skutecznie blokuje zrzuty ekranu i nagrywanie systemowe. Na desktopie skuteczność jest ograniczona (aplikacja z prawami root może ominąć blokadę).

Warstwa 2 — Visible watermark: Opcjonalny widoczny watermark nakładany na strumień pikseli: operator_id, timestamp, semi-transparent. Zniechęca do fotografowania ekranu aparatem (camera capture).

Warstwa 3 — Invisible watermark: Steganograficzny watermark w strumieniu pikseli (per-frame, per-operator) umożliwiający identyfikację źródła w przypadku wycieku zrzutu ekranu.

Warstwa 4 — Behavioral detection: Session Broker monitoruje wzorce użycia: nagle zatrzymanie inputu + pozycja terminala wskazująca na fotografowanie (opcjonalnie: czujnik front camera na Pixel wykrywa zbliżenie innego urządzenia — eksperymentalne, inwazyjne).

Realistyczna ocena: Pełna ochrona przed screen capture jest fizycznie niemożliwa — operator może zawsze sfotografować ekran aparatem innego urządzenia. SYLION minimalizuje ryzyko przez: watermarking (identyfikacja sprawcy), FLAG_SECURE (blokada softwarowa), audyt (monitoring wzorców), szkolenie operatorów (awareness). Akceptacja ryzyka residualnego jest wymagana.

37.13. Izolacja per-sesja i per-operator

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 37.1, 38.1, 38.2

Każda sesja streamingowa jest izolowana — Session Broker zapewnia:

Izolacja per-sesja: - Osobny kontekst enkodera wideo (dedykowana instancja lub wątek) - Osobny bufor schowka - Osobne tokeny sesji - Osobny kanał audio - Brak współdzielenia stanu między sesjami różnych operatorów

Izolacja per-operator: - Sesje różnych operatorów są izolowane na poziomie procesu lub kontenera Session Broker - Brak możliwości cross-session communication (operator A nie widzi sesji operatora B) - Brak współdzielenia cache enkodera między operatorami

Implementacja: Rekomendowane: dedykowana instancja Session Broker per operator (microVM lub kontener). Alternatywne: współdzielona instancja Session Broker z izolacją per-session (multi-tenant) — akceptowalna dla STANDARD/PRO, niezalecana dla STATE.

Dla tieru STATE: dedykowana instancja Session Broker per operator, działająca w osobnej microVM Firecracker z izolacją na poziomie hosta (AMD SEV-SNP / Intel TDX).

37.14. Broker jako SPOF — ograniczenia i mitigacje

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 37.1, 37.13, 36.9

Session Broker jest potencjalnym Single Point of Failure (SPOF) — jego awaria oznacza utratę sesji streamingowej dla operatora.

Mitigacje: 1. HA per operator: Dla operatorów krytycznych — dedykowany Session Broker z automatycznym failover na standby. Failover: < 15 sekund (operator widzi krótkie zawieszenie obrazu, nie utratę danych) 2. Pool brokerów: Wiele instancji Session Broker z load balancingiem (G2 routing — 36.9). Utrata jednego brokera → operatorzy przypisani do tego brokera ustanawiają nową sesję na innym (automatycznie) 3. Stateless broker: Broker nie przechowuje stanu roboczego operatora — stan jest w workloadzie. Restart brokera wymaga jedynie ponownego ustanowienia sesji streamingowej (obraz pulpitu jest odtwarzany z workloadu) 4. Graceful reconnect: Klient na terminalu automatycznie ponawia połączenie po utracie sesji (exponential backoff, max 30 sekund)

Czas odtworzenia sesji: - Restart brokera: < 10 sekund (odtworzenie capture + encode pipeline) - Failover na nowy broker: < 30 sekund (nowa sesja, pełna re-autentykacja) - Rebuild workloadu (scenariusz worst-case): 2–5 minut (38.11)

Akceptowalny downtime sesji: < 60 sekund (SLA wewnętrzny).

37.15. Model Hypori — szyfrowany pixel streaming

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 37.1, 37.5, 41.11

Model Hypori (nazwa od produktu Hypori Halo) definiuje architekturę, w której dane nigdy nie opuszczają chmury — terminal wyświetla wyłącznie strumień pikseli, a wszelkie przetwarzanie odbywa się po stronie serwera.

Implementacja w SYLION: 1. Workload renderuje pulpit/aplikację w framebuffer 2. Session Broker przechwytuje framebuffer (DMA-BUF / screen capture API) 3. Framebuffer jest encodowany (H.264/H.265/AV1) sprzętowo lub programowo 4. Zakodowany strumień jest szyfrowany (TLS 1.3 lub DTLS 1.3) 5. Strumień jest transmitowany do terminala przez tunel IPsec (double encryption: IPsec + TLS — celowe: defense in depth) 6. Terminal dekoduje sprzętowo i wyświetla na ekranie 7. Dane z framebuffera nigdy nie są zapisywane na terminalu — dekodowany frame jest bezpośrednio renderowany w buforze wyświetlacza

Korzyści: - Zero-data-at-rest na terminalu: nawet pamięć terminala nie zawiera dekodowanego obrazu dłużej niż czas wyświetlania jednego frame - Utrata terminala = utrata pustego urządzenia - Kontrola nad danymi jest całkowita — administrator może w dowolnym momencie zamknąć sesję i dane znikają z terminala

Ograniczenia: - Wymagane stałe połączenie sieciowe (brak trybu offline) - Jakość zależna od łącza (latencja, bandwidth) - Intensywność obliczeniowa po stronie serwera (encode per operator)

37.16. Blind Broker i jego limity [E]

Status: [E] Eksperymentalny Odbiorca: Architekt (R&D) Wpływ na baseline: Niski (nie w produkcji) Powiązane rozdziały: 37.1, 37.15, 41.11

Blind Broker to koncepcja eksperymentalna, w której Session Broker przekazuje strumień pikseli i audio bez możliwości ich odczytania — strumień jest szyfrowany end-to-end (terminal ↔ workload), a broker pełni wyłącznie rolę relay.

Cel: Eliminacja brokera jako trusted party — nawet kompromitacja brokera nie ujawnia treści sesji.

Koncepcja: - Workload szyfruje framebuffer kluczem sesji uzgodnionym bezpośrednio z terminalem (ECDH) - Session Broker przekazuje zaszyfrowany strumień — nie ma klucza sesji - Terminal deszyfruje i dekoduje framebuffer

Limity: 1. Broker nie może nakładać watermarku (nie widzi treści) → wymaga watermarku na poziomie workloadu 2. Broker nie może egzekwować polityk eksportowych na strumieniu (nie widzi co jest wyświetlane) → wymaga egzekwowania wyłącznie na workloadzie 3. Adaptacyjny bitrate jest trudniejszy — broker nie widzi treści, nie może ocenić złożoności obrazu 4. Inspekcja DLP na strumieniu jest niemożliwa 5. Debugging i troubleshooting jakości sesji jest utrudniony

Ocena: Blind Broker znacząco zwiększa bezpieczeństwo (zero trust even for infrastructure), ale kosztem utraty możliwości kontroli i obserwowalności. Dla produkcyjnego SYLION (baseline) — Session Broker jest trusted party. Blind Broker jest badany jako opcja dla scenariuszy o najwyższych wymaganiach (STATE+ / sovereign).

37.17. Control plane vs media plane

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 37.5, 37.6, 41.2

Architektura Session Broker rozdziela control plane od media plane:

Control plane: - Sygnalizacja sesji: ustanowienie, odnowienie tokena, terminowanie - Wymiana parametrów: rozdzielczość, kodek, bitrate - Polityki: clipboard, file redirect, print (decyzje G2) - Heartbeat sesji - Protokół: HTTPS (REST API lub gRPC) over TLS 1.3 - Charakterystyka: niski wolumen, wysoka niezawodność (TCP), nie toleruje utraty pakietów

Media plane: - Strumień pikseli (video encoded) - Strumień audio (Opus) - Protokół: UDP (DTLS/SRTP) lub WebRTC - Charakterystyka: wysoki wolumen, toleruje utratę pakietów (video/audio — degradacja graceful), wymaga niskiej latencji

Separacja: Control plane i media plane mogą (i powinny) przechodzić różnymi ścieżkami sieciowymi i być niezależnie skalowane. Control plane jest obsługiwany przez komponent stateful (session manager), media plane przez komponent stateless (media relay/encoder).

Separacja umożliwia: (a) niezależne skalowanie encode capacity (dodawanie media nodes), (b) failover control plane bez utraty media (krótkookresowej), (c) różne polityki QoS (34.6) per plane.

37.18. Decyzje architektoniczne dla production baseline

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 37.1–37.17

Podsumowanie kluczowych decyzji architektonicznych Session Broker dla produkcyjnego baseline SYLION:

Decyzja	Wybór	Uzasadnienie
Tryb domyślny	Limited workspace (37.3)	Balans UX i bezpieczeństwa
Protokół media	Custom pixel stream (H.264 over WebRTC/DTLS)	Najniższa latencja, pełna kontrola
Audio	Opus 48 kHz	Najlepsza jakość/bitrate
Clipboard out	Zablokowany (STANDARD/STATE), ograniczony (PRO)	DLP
File redirect	Wyłączony (all tiers)	CDR pipeline zamiast
Print	Zablokowany (STANDARD), z CDR (PRO), dual auth (STATE)	DLP
Screen capture	FLAG_SECURE + invisible watermark	Best effort protection
Izolacja	Per-operator Session Broker (STATE), shared (STANDARD/PRO)	Proportjonalne do ryzyka
Blind Broker	Nie (eksperymentalny)	Brak gotowości produkcyjnej
HA	Pool brokerów + auto-reconnect	SLA < 60s downtime
Szyfrowanie	TLS 1.3 (control) + DTLS (media) + IPsec (transport)	Defense in depth

Rozdział 38. Środowiska operatorów i workload orchestration

38.1. Zasada strefy per operator

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.3, 37.1, 38.2

W architekturze SYLION każdy operator posiada dedykowaną strefę w Zone 3 — logicznie (i w miarę możliwości fizycznie) izolowany zestaw workloadów. Strefa operatora obejmuje: env-matrix, env-signal, env-browser, env-office, env-crm, env-voice oraz opcjonalne workloady custom.

Zasada fundamentalna: Dane i procesy operatora A nie są dostępne dla operatora B. Nie istnieje współdzielony storage, współdzielona pamięć ani współdzielona sieć między strefami operatorów (poza usługami wspólnymi w Zone 4, dostępnymi przez kontrolowane API).

Implementacja: - Każdy operator ma dedykowaną namespace (Kubernetes) lub grupę microVM (Firecracker) lub grupę kontenerów (rootless Podman) - Networking: dedykowany VLAN lub VXLAN per operator (mikrosegmentacja Layer 2) lub network policy per namespace (mikrosegmentacja Layer 3/4) - Storage: dedykowany wolumen per workload, szyfrowany kluczem per operator (key-per-tenant) - Secrets: dedykowane sekrety per operator w Vault (namespace isolation)

Koszt vs. bezpieczeństwo: Pełna izolacja per operator jest kosztowna (osobna infrastruktura per user). SYLION skaluje izolację z tierem: - STANDARD: namespace isolation (Kubernetes) + network policy + per-user encrypted volume - PRO: microVM per workload (Firecracker) + VLAN per operator + per-user encrypted volume - STATE: dedicated host per operator (lub mała grupa operatorów) + microVM + VLAN + hardware memory isolation (AMD SEV-SNP / Intel TDX)

38.2. Zasada izolacji per workload

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 38.1, 38.3, 38.4

W ramach strefy operatora każdy workload (env-matrix, env-browser, env-office itd.) jest izolowany od pozostałych. Kompromitacja jednego workloadu nie powinna skutkować kompromitacją pozostałych.

Uzasadnienie: Workloady mają różne profile ryzyka: env-browser jest narażony na ataki webowe (drive-by download, malicious JavaScript), env-signal komunikuje się z zewnętrzną infrastrukturą (serwery Signal), env-office przetwarza pliki (potencjalnie złośliwe). Izolacja zapobiega lateralnemu ruchowi — exploit w przeglądarce nie daje dostępu do Matrix ani CRM.

Implementacja izolacji per workload: - Minimalny model (STANDARD): rootless kontener per workload, osobna sieć (network namespace), osobny storage (bind mount z dedykowanego katalogu) - Rekomendowany model (PRO): microVM Firecracker per workload — pełna izolacja VM z dedykowanym kernelem, minimalnym rootfs i ograniczonym I/O - Maksymalny model (STATE): microVM + AMD SEV-SNP / Intel TDX (confidential computing) — pamięć workloadu jest zaszyfrowana kluczem nieznanym hostowi

Komunikacja między workloadami tego samego operatora: - Domyślnie: brak (no cross-workload communication) - Wyjątek: kontrolowane API w Zone 4 (np. env-crm odpytuje API w Zone 4, env-matrix odpytuje to samo API — ale nie komunikują się bezpośrednio) - Wyjątek dla clipboard: cross-workload clipboard dozwolony w PRO (przez Session Broker proxy — 37.9)

38.3. Minimalny model izolacji

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 38.1, 38.2, 38.5

Model minimalny izolacji jest baseline dla tieru STANDARD:

Technologia: Rootless Podman containers (lub runc/crun runtime)

Izolacja: - Każdy workload = osobny kontener z dedykowanym user namespace (rootless — brak uprawnień root na hoście) - Network: osobna network namespace per kontener, brak łączności między kontenerami (no default bridge) - PID: osobna PID namespace (procesy kontenera niewidoczne z innych kontenerów) - Mount: osobny mount namespace, dedykowany tmpfs, bind mount dla persisted data - IPC: osobna IPC namespace (brak shared memory między kontenerami)

Dodatkowe hardening: - seccomp profil (restricted — blokada syscalls: mount, ptrace, kexec_load, pivot_root itp.) - AppArmor/SELinux profil per workload - Capabilities: CAP_NET_RAW dropped, CAP_SYS_ADMIN dropped, minimalne capabilities - Read-only rootfs (dane w dedykowanym wolumenie)

Ograniczenia modelu minimalnego: - Kontenery współdzielą kernel hosta — exploit kernel = ucieczka ze wszystkich kontenerów - Rootless containers mają ograniczenia wydajnościowe (user namespace overhead) - Brak izolacji pamięci na poziomie hardware (brak SEV-SNP/TDX)

Model minimalny jest akceptowalny dla STANDARD, gdzie dane są mniej wrażliwe. Dla PRO i STATE — wymagane jest przejście na model rekomendowany lub maksymalny.

38.4. Rekomendowany model izolacji

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 38.3, 38.5, 38.6

Model rekomendowany jest baseline dla tieru PRO i rekomendowany minimum dla STATE:

Technologia: Firecracker microVM

Architektura: - Każdy workload = osobna microVM Firecracker z dedykowanym kernelem (minimalistyczny, hardened) - Rootfs: read-only squashfs lub ext4 snapshot - RAM: przydzielona z puli hosta, izolowana przez VMM (Virtual Machine Monitor) - CPU: vCPU pinned lub shared (cgroups v2 na hoście) - Network: TAP interface per microVM, firewall per-VM na hoście

UWAGA INFRASTRUKTURALNA: Firecracker i nested virtualization. Firecracker wymaga dostępu do /dev/kvm (KVM hypervisor). Typowe VPS za €20/mc (Hetzner Cloud, OVH Public Cloud) są same maszynami wirtualnymi i NIE udostępniają nested virtualization domyślnie. Rozwiązania: (1) STANDARD tier: rootless containers (Podman) dla WSZYSTKICH workloadów — nie wymaga KVM, koszt €20/VPS; (2) PRO tier: VPS z nested virt (Hetzner Dedicated, OVH Bare Metal Eco) — koszt ~€40–80/serwer, dzielony między operatorów; (3) STATE tier: dedicated bare-metal z pełnym dostępem KVM — koszt ~€80–200/serwer. Model kosztowy €86/user/mc jest realistyczny dla STANDARD (Podman), ale zaniżony o ~€15–40/user/mc dla PRO/STATE z Firecracker.

Firecracker: Firecracker jest lekkim VMM stworzonym przez AWS (open source, Rust), zoptymalizowanym pod microVM: - Boot time: < 125 ms - Memory overhead: < 5 MB per VM - Minimalny device model (brak PCI, brak ACPI, brak legacy) — mała powierzchnia ataku - Jailer: Firecracker działa w jail (seccomp + cgroups + namespaces) — nawet exploit VMM jest ograniczony

Zalety: - Izolacja na poziomie VM — exploit kernel gościa nie wpływa na hosta (kernel hosta jest oddzielny) - Deterministyczny boot — każda microVM startuje z identycznego image (immutable infrastructure) - Szybkie odtwarzanie — restart microVM < 1 sekunda (38.11)

Rekomendowane konfiguracje workloadów:

Workload	vCPU	RAM	Rootfs	Storage
env-matrix	1	512 MB	Alpine + Element	1 GB
env-signal	1	512 MB	Alpine + Signal Desktop	1 GB
env-browser	2	2 GB	Alpine + Chromium	2 GB
env-office	2	2 GB	Alpine + LibreOffice	5 GB
env-crm	2	1 GB	Alpine + CRM client	2 GB
env-voice	1	512 MB	Alpine + VoIP client	512 MB

38.5. VM, microVM, rootless containers — porównanie

Status: [R] Rekomendowany Odbiorca: Architekt Wpływ na baseline: Średni Powiązane rozdziały: 38.3, 38.4, 38.6

Kryterium	Rootless container	Firecracker microVM	Full VM (QEMU/KVM)
Izolacja kernel	Współdzielony	Osobny (guest kernel)	Osobny (guest kernel)
Izolacja pamięci	Namespace + cgroups	VMM + opcja SEV-SNP	VMM + opcja SEV-SNP
Boot time	< 1 s	< 125 ms	5–30 s
Memory overhead	< 10 MB	< 5 MB	50–200 MB
Surface attack	Kernel hosta + container runtime	Firecracker VMM (~50k LOC Rust)	QEMU (~1.5M LOC C)
Device model	Host devices (limited)	Minimal (virtio-net, virtio-block)	Full (PCI, USB, ACPI)
GPU/HW acceleration	Bezpośredni (cgroups device)	Brak (brak PCI passthrough)	Możliwy (PCI passthrough)
Immutability	Dobra (read-only rootfs)	Doskonała (snapshot rootfs)	Dobra
Koszt per operator	Niski	Średni	Wysoki
Tier SYLION	STANDARD	PRO	STATE (specjalne)

Wybór: - STANDARD: rootless containers (koszt, wystarczająca izolacja) - PRO: Firecracker microVM (lepsz izolacja, akceptowalny koszt) - STATE: Firecracker + SEV-SNP/TDX lub Full VM z SEV-SNP (najwyższa izolacja)

38.6. Wybór poziomu izolacji na podstawie ryzyka

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 38.3, 38.4, 38.5

Poziom izolacji jest determinowany przez: (a) tier operatora, (b) profil ryzyka workloadu, (c) wrażliwość danych.

Matryca izolacji:

Workload	Profil ryzyka	STANDARD	PRO	STATE
env-browser	Wysoki (ataki web)	Container	microVM	microVM + SEV
env-signal	Wysoki (zewn. infra)	Container	microVM	microVM + SEV

env-matrix	Średni	Container	microVM	microVM + SEV
env-office	Średni (pliki)	Container	microVM	microVM + SEV
env-crm	Niski (wewnętrzny)	Container	Container/microVM	microVM + SEV
env-voice	Niski	Container	Container	microVM

Profil ryzyka workloadu: - Wysoki: workload komunikuje się z niekontrolowaną infrastrukturą (internet, zewnętrzne API) lub przetwarza niezaufane dane (strony web, pliki od zewnętrznych podmiotów) - Średni: workload komunikuje się z kontrolowaną infrastrukturą (Zone 4 services) i przetwarza dane wewnętrzne - Niski: workload nie ma egress do internetu i przetwarza wyłącznie dane wewnętrzne

38.7. Storage per workload

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 38.1, 38.2, 47.7

Każdy workload posiada dedykowany wolumen storage:

Rodzaje storage: - Rootfs (read-only): Obraz bazowy workloadu (OS + aplikacje). Współdzielony (CoW — Copy-on-Write) między instancjami tego samego workloadu. Immutable — nie modyfikowany w runtime - Data volume (read-write): Dane robocze operatora per workload. Dedykowany, szyfrowany, backupowany - Tmpfs (ephemeral): Tymczasowe dane (cache, sesje aplikacji). Utracone przy restarcie workloadu

Szyfrowanie: Data volume jest szyfrowany: - LUKS2 per volume z kluczem per operator (key-per-tenant) - Klucz jest przechowywany w Vault (46.5) i dostarczany do workloadu przy starcie (auto-unseal) - Klucz nie jest przechowywany na hoście w formie jawnej — dostarczany przez API Vault, przechowywany wyłącznie w pamięci hosta na czas działania workloadu

Quota: | Workload | Storage limit (STANDARD) | Storage limit (PRO) | Storage limit (STATE) | |—|—|—|—| env-matrix | 1 GB | 5 GB | 20 GB | | env-browser | 2 GB | 5 GB | 10 GB | | env-office | 5 GB | 20 GB | 100 GB | | env-crm | 2 GB | 10 GB | 50 GB | | env-signal | 1 GB | 2 GB | 5 GB | | env-voice | 512 MB | 1 GB | 2 GB |

Przekroczenie quota: workload otrzymuje alert, nowe zapisy są blokowane. Administrator może zwiększyć quota (change management).

38.8. Namespace, cgroups, seccomp, AppArmor, SELinux

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 38.3, 38.4, 38.5

Każdy workload (kontener lub microVM) podlega wielowarstwowemu hardening na poziomie hosta:

Linux Namespaces: - PID namespace: procesy workloadu widzą wyłącznie własne procesy (PID 1 = init workloadu) - Network namespace: osobny stos sieciowy (interfejsy, routing, firewall). Brak widoczności sieci hosta - Mount namespace: osobne montowania. Rootfs read-only, data volume read-write - User namespace: mapowanie UID/GID — root w workloadzie = non-root na hoście (rootless) - IPC namespace: osobna przestrzeń IPC (shared memory, semafony) - UTS namespace: osobna hostname

cgroups v2: - CPU: max vCPU per workload (38.13) - Memory: hard limit (OOM killer w workloadzie, nie na hoście) - I/O: throttling (max IOPS, max bandwidth) per workload - PIDs: max liczba procesów (zapobieganie fork bomb)

seccomp: Profil seccomp ogranicza dozwolone syscale: - Bazowy: allowlist ~200 syscali (z 400+ dostępnych) - Zablokowane: mount, umount, ptrace, kexec_load, pivot_root, reboot, sethostname, setdomainname, swapon/off, init_module, delete_module - Dla env-browser: dodatkowe blokady (np. clone z flagami CLONE_NEWUSER — zapobieganie namespace escape)

AppArmor / SELinux: - AppArmor (preferowany na Ubuntu/Debian): profil per workload definiujący dozwolone ścieżki plików, capabilities, sieć - SELinux (na RHEL/Fedora): typ per workload z dedykowaną polityką MLS/MCS

Polityki są generowane automatycznie na podstawie szablonu per typ workloadu i audytowane co 90 dni.

38.9. Egress per workload

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 38.2, 42.13, 45.9

Każdy workload ma ściśle zdefiniowane dozwolone połączenia wychodzące (egress):

Workload	Dozwolony egress
env-matrix	Matrix homeserver (Zone 4), federacja (jeśli dozwolona)
env-signal	Serwery Signal (internet, przez proxy w Zone 4)
env-browser	Internet (przez forward proxy w Zone 4 z filtracją)
env-office	Zone 4 services (file storage, API), brak internetu
env-crm	Zone 4 CRM API, brak internetu
env-voice	Media plane (Zone 4 / internet przez proxy)

Implementacja: Firewall per workload (nftables na hoście lub network policy w Kubernetes): - Default: DROP outbound - Allowlist: konkretne IP/porty per workload - DNS: wyłącznie resolver SYLION (Zone 4) — brak bezpośrednich zapytań DNS do internetu

Forward proxy (Zone 4): Workloady wymagające dostępu do internetu (env-browser, env-signal) łączą się przez forward proxy (Squid lub Envoy) w Zone 4. Proxy: (a) loguje wszystkie żądania (URL, metadata — nie treść dla HTTPS), (b) blokuje domeny z threat intelligence, (c) stosuje content filtering (opcjonalnie), (d) wymusza TLS inspection (dla env-browser — kontrowersyjne, opcjonalne).

Egress jest kluczowym mechanizmem ograniczającym exfiltrację — nawet jeśli workload jest skompromitowany, nie może komunikować się z dowolnym adresem w internecie.

38.10. Ruch między workloadami

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 38.2, 38.9, 43.1

Komunikacja bezpośrednia między workloadami tego samego operatora jest domyślnie zablokowana.

Uzasadnienie: Izolacja per workload (38.2) traci sens, jeśli workloady mogą swobodnie komunikować się między sobą. Kompromitacja env-browser mogłaby prowadzić do ataku na env-matrix przez sieć wewnętrzną.

Dozwolona komunikacja (wyłącznie przez Zone 4): Jeśli workloady potrzebują współdzielić dane (np. plik z env-office do env-crm), komunikacja odbywa się przez API w Zone 4 (usługi wspólne — Rozdział 43): 1. env-office uploaduje plik do shared storage API (Zone 4) z CDR 2. env-crm pobiera plik z shared storage API (Zone 4) z CDR 3. Brak bezpośredniej komunikacji sieciowej env-office ↔ env-crm

Wyjątek: Dla tieru PRO/STATE administrator może jawnie dozwolnić komunikację między wybranymi workloadami (np. env-matrix ↔ env-voice dla integracji VoIP). Wyjątek wymaga: (a) uzasadnienia, (b) akceptacji ryzyka, (c) ograniczenia do konkretnych portów/protokołów, (d) logowania, (e) audytu.

38.11. Rebuild pojedynczego workloadu

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 38.4, 38.7, 49.3

Workload może być zbudowany od nowa (rebuild) w przypadku: (a) podejrzenia kompromitacji, (b) awarii, (c) aktualizacji image bazowego, (d) żądania operatora (reset).

Procedura rebuild: 1. Session Broker zamyka sesję operatora do danego workloadu 2. Workload (microVM/kontener) jest zatrzymywany 3. Data volume jest: (a) zachowany (rebuild z zachowaniem danych), lub (b) wymazany (clean rebuild) 4. Nowa instancja workloadu jest uruchamiana z aktualnego image bazowego 5. Data volume jest podmontowany (jeśli zachowany) 6. Sekrety (klucze, tokeny) są dostarczane z Vault 7. Healthcheck → workload dostępny 8. Session Broker przywraca sesję

Czas rebuild: - Firecracker microVM: < 5 sekund (boot + mount) - Kontener: < 3 sekundy - Pełna microVM (QEMU): < 30 sekund

Clean rebuild: Stosowany w przypadku podejrzenia kompromitacji — data volume jest wymazywany. Dane operatora są odtwarzane z backupu (jeśli dostępny) po przeskanowaniu.

Automatyczny rebuild: Dla workloadów stateless (env-browser, env-signal) automatyczny rebuild co 24 godziny (STANDARD/PRO) lub co 12 godzin (STATE) — rotacja środowiska zapobiega persistence malware.

38.12. Rebuild całego środowiska operatora

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 38.11, 38.1, 50.7

Rebuild całego środowiska operatora obejmuje rebuild wszystkich workloadów jednocześnie. Stosowany w przypadku: (a) potwierdzony kompromis operatora (lateral movement), (b) zmiana tieru operatora, (c) migracja na nowy host, (d) offboarding operatora (clean destroy).

Procedura: 1. Zamknięcie wszystkich sesji operatora 2. Unieważnienie wszystkich tokenów i kluczy sesji 3. Zatrzymanie wszystkich workloadów 4. Backup data volumes (jeśli rebuild, nie destroy) 5. Wymazanie stanu (cgroups, namespaces, wolumeny tymczasowe) 6. Ponowne uruchomienie workloadów z czystych image 7. Przywrócenie data volumes z backupu (jeśli rebuild, nie destroy) 8. Nowe sekrety z Vault 9. Healthcheck → przywrócenie dostępu

Czas: < 5 minut (wszystkie workloady równolegle).

Destroy (offboarding): Wymazanie wszystkich data volumes, unieważnienie kluczy, usunięcie namespace, usunięcie wpisów w IAM i Asset Inventory. Dane operatora: retencja zgodna z polityką organizacyjną i RODO.

38.13. Limity zasobów i governance

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Średni Powiązane rozdziały: 38.4, 38.7, 38.8

Każdy workload operuje w ramach zdefiniowanych limitów zasobów:

Zasób	Limit per workload	Limit per operator	Uwagi
vCPU	1–4 (zależny od workloadu)	8 (STANDARD), 16 (PRO), 32 (STATE)	Burstable
RAM	512 MB – 4 GB	4 GB (STANDARD), 16 GB (PRO), 64 GB (STATE)	Hard limit
Storage	Per workload (38.7)	Suma quota workloadów	Quota per volume
Network bandwidth	100 Mbps (STANDARD), 500 Mbps (PRO), 1 Gbps (STATE)	Per operator	Shaping
PIDs (processes)	256 per workload	1024 per operator	Fork bomb protection
Open files	4096 per workload	16384 per operator	ulimit

Przekroczenie limitu: - CPU: throttling (cgroups CPU quota) — spowolnienie, nie kill - RAM: OOM killer w workloadzie (nie na hoście) — restart workloadu - Storage: zapisy blokowane, alert - Network: shaping (tc/cake) — spowolnienie, nie drop - PIDs: nowe procesy odrzucane (EAGAIN)

Governance: limity są konfigurowane per tier i per workload type. Zmiana limitu wymaga change management. Monitoring utilization pozwala na planowanie capacity.

38.14. Obserwowalność workloadów

Status: [N] Normatywny Odbiorca: Administrator, SOC Wpływ na baseline: Średni Powiązane rozdziały: 38.8, 38.13, 46.6

Obserwowalność workloadów obejmuje zbieranie metryk, logów i trases bez ingerencji w prywatność operatora.

Metryki (per workload): - CPU utilization, memory utilization, disk I/O, network I/O - Proces count, open file count - Uptime, restart count - Healthcheck status

Logi (per workload): - Logi systemowe (syslog) — agregowane do SIEM - Logi aplikacji (stdout/stderr) — opcjonalnie - Nie logowane: treść komunikacji, treść dokumentów, input operatora (klawiatury)

Traces: - Distributed tracing (OpenTelemetry) dla żądań service-to-service (workload ↔ Zone 4) - Przydatne dla troubleshootingu (dlaczego env-crm jest wolny?)

Alerty: - Workload down: restart automatyczny (38.11), alert po 3 restartach w 10 minut - Workload resource exhaustion: alert przy 90% limitu - Anomalia sieciowa: nietypowy egress (nowy adres docelowy, nietypowy wolumen) - Anomalia procesowa: nietypowy proces (np. reverse shell, crypto miner)

Obserwowalność jest balansem między bezpieczeństwem (potrzeba detekcji) a prywatnością (operator ma prawo do poufnej pracy). SYLION loguje metadane i metryki, nie treść.

Rozdział 39. Matrix jako rdzeń komunikacyjny

39.1. Uzasadnienie wyboru Matrix

Status: [N] Normatywny Odbiorca: Architekt, Decydent Wpływ na baseline: Krytyczny Powiązane rozdziały: 40.1, 41.1, 43.6

Matrix (matrix.org) jest wybrany jako rdzeń komunikacyjny SYLION z następujących powodów:

Otwarty protokół (Apache 2.0): Brak vendor lock-in. Specyfikacja protokołu jest publiczna i implementowalna przez dowolny podmiot. Zgodność z zasadą sovereign software

Federacja: Matrix natywnie wspiera federację — homeservery różnych organizacji mogą komunikować się między sobą. Umożliwia to międzyorganizacyjną komunikację bezpieczną (np. między agencjami rządowymi używającymi SYLION)

End-to-End Encryption (E2EE): Matrix implementuje Megolm/Olm (bazujące na protokole Double Ratchet, jak Signal Protocol). Szyfrowanie jest domyślne dla Direct Messages i opcjonalne (zalecane) dla pokoi grupowych

Wieloplatformowość klientów: Element (reference client) działa na Android, iOS, Web, Desktop. Alternatywne klienty: FluffyChat, SchildiChat, Nheko

Adopcja w sektorze publicznym: Matrix jest oficjalnym komunikatorem Bundeswehr (BwMessenger), francuskiego rządu (Tchap), NATO ACT (NCI Agency).

Dojrzałość sektora publicznego jest kluczowa dla tieru STATE

Self-hosted: Homeserver może być w pełni hostowany on-premise — brak zależności od zewnętrznej infrastruktury

Rozszerzalność: Boty, widżety, integracje (bridges) — Matrix może łączyć się z innymi systemami

Alternatywy rozważane i odrzucone: - Signal: Brak federacji, brak self-hosted serwera (patrz Rozdział 40), centralny punkt awarii - XMPP: Fragmentacja implementacji, gorsze UX, mniejsza adopcja - Mattermost/Rocket.Chat: Proprietary z open-core, brak standardu protokołu, brak natywnej federacji E2EE - Custom: Zbyt duży koszt i ryzyko implementacji

39.2. Zakres użycia Matrix w SYLION

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 39.1, 41.1, 43.6

Matrix w SYLION obsługuje:

Komunikacja tekstowa: Wiadomości 1:1 (Direct Messages), pokoje grupowe, kanały organizacyjne

Wymiana plików: Pliki przesyłane przez Matrix przechodzą CDR pipeline (42.6) — homeserver integruje się z CDR na wejściu

Voice/Video calls: Przez Element/Matrix (VoIP — Jitsi integration lub native Matrix VoIP). Media plane — patrz Rozdział 41

Powiadomienia systemowe: Boty Matrix dostarczają powiadomienia z SIEM, CI/CD, monitoring (np. alert o incydencie, status deploymentu)

Integracje: Bridges do zewnętrznych systemów (opcjonalnie, kontrolowane) — np. bridge do email (dla powiadomień), bridge do SMS (ograniczony)

Nie-zakres: Matrix NIE jest używany do: przechowywania dokumentów (→ env-office), zarządzania projektami (→ env-crm), analityki (→ dedykowany workload). Matrix jest komunikatorem, nie platformą productivity.

Deployment: Matrix homeserver działa jako usługa w Zone 4 (shared services) — wspólna instancja dla wszystkich operatorów danego tenanta. Klient Matrix (Element) działa w workloadzie env-matrix per operator (Zone 3). Operator łączy się z homeserverem z env-matrix przez wewnętrzną sieć (Zone 3 → Zone 4).

39.3. Model tożsamości i federacji

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 39.1, 44.1, 44.10

Tożsamość Matrix: Identyfikator użytkownika Matrix w SYLION: @operator_id:sylon.tenant.example.com — operator jest identyfikowany przez swój operator_id, a homeserver przez domenę tenanta.

Uwierzytelnienie do homeservera: SSO (OIDC) zintegrowane z IAM SYLION (44.10). Operator loguje się do env-matrix, klient Element uwierzytelnia się w homeserverze przez token OIDC wystawiony przez IdP SYLION. Brak osobnego hasła do Matrix.

Federacja: Matrix natywnie wspiera federację — homeservery SYLION mogą komunikować się z homeserverami innych organizacji (innych tenantów SYLION lub zewnętrznych homeserwerów Matrix).

Polityka federacji: | Scenariusz | STANDARD | PRO | STATE | |—|—|—| | Federacja wewnątrz SYLION (między tenantami) | Dozwolona | Dozwolona | Dozwolona (allowlist) | | Federacja z zewnętrznymi homeserverami | Dozwolona (allowlist) | Dozwolona (allowlist) | Zablokowana (default) | | Federacja z matrix.org (publiczna) | Zablokowana | Zablokowana | Zablokowana |

Allowlist federacji: administrator definiuje listę domen, z którymi homeserver SYLION może federować. Domeny spoza listy → federacja zablokowana.

Dla tieru STATE domyślnie: brak federacji (dark homeserver — izolowany, 39.10). Federacja dozwolona wyłącznie po jawnym włączeniu i akceptacji ryzyka.

39.4. Warianty homeservera (Synapse, Dendrite, Conduit)

Status: [R] Rekomendowany Odbiorca: Architekt, Administrator Wpływ na baseline: Średni Powiązane rozdziały: 39.1, 39.2

Homeserver	Język	Dojrzałość	Wydajność	Rekomendacja SYLION
Synapse	Python	Najwyższa (referencyjny)	Średnia (RAM-heavy)	Domyślny (STANDARD/PRO)
Dendrite	Go	Dobra (beta→stable)	Wysoka (niski RAM)	Rekomendowany (PRO/STATE)
Conduit	Rust	Wczesna (experimental)	Bardzo wysoka	Eksperymentalny, nie do produkcji

Synapse: Synapse jest referencyjną implementacją Matrix Protocol. Zalety: pełna zgodność ze specyfikacją, największa baza użytkowników, najlepiej przetestowany. Wady: wysokie zużycie RAM (> 1 GB dla >100 użytkowników), Python — ograniczona wydajność. Rekomendowany dla: małych deploymentów (< 200 użytkowników), gdzie stabilność jest priorytetem.

Dendrite: Dendrite jest drugą generacją homeservera Matrix, napisaną w Go. Zalety: znacznie niższe zużycie RAM, lepsza skalowalność (architektura microservices), szybsza. Wady: nowsza, mniej przetestowana. Rekomendowany dla: większych deploymentów, tieru STATE (niższe zużycie zasobów = mniejsza powierzchnia ataku).

Conduit: Conduit jest eksperymentalnym homeserverem w Rust. Bardzo wydajny, minimalny footprint. Nie rekomendowany do produkcji — brak pełnej zgodności ze specyfikacją.

39.5. Retencja, polityki danych i kontrola organizacyjna

Status: [N] Normatywny Odbiorca: Administrator, DPO Wpływ na baseline: Wysoki Powiązane rozdziały: 39.2, 42.14, 44.1

Homeserver Matrix przechowuje historię wiadomości i metadane. Polityki retencji i danych muszą być jawnie skonfigurowane.

Retencja wiadomości: | Typ | STANDARD | PRO | STATE | |---|---|---| Direct Messages | 90 dni | 365 dni | Konfigurowalne (1–3650 dni) | | Pokoje grupowe | 90 dni | 365 dni | Konfigurowalne | | Pliki/załączniki | 30 dni | 90 dni | Konfigurowalne |

Po upływie retencji: wiadomości i pliki są automatycznie usuwane z homeservera (purge). Usunięcie jest nieodwracalne — backup jest jedynym mechanizmem retencji dłuższej.

Kontrola organizacyjna: Administrator SYLION ma kontrolę nad: - Tworzeniem pokoi (kto może tworzyć, polityka nazewnictwa) - Zaproszeniami (kto może zapraszać, limity per operator) - Uprawnieniami w pokojach (moderacja, power levels) - Widocznością pokoi (publiczne vs. prywatne w obrębie organizacji) - Integracjami i botami (allowlist)

RODO/GDPR: Operator ma prawo do: (a) dostępu do swoich danych (eksport wiadomości), (b) usunięcia danych (account deactivation + purge), (c) przeniesienia danych (eksport w formacie JSON). Administrator musi zapewnić procedury obsługi tych żądań.

39.6. Integracje wewnętrzne

Status: [R] Rekomendowany Odbiorca: Administrator, DevOps Wpływ na baseline: Niski Powiązane rozdziały: 39.2, 43.1, 48.1

Matrix może integrować się z wewnętrznymi systemami SYLION przez boty i webhooks:

SIEM bot: Dostarcza alerty bezpieczeństwa do dedykowanego pokoju Matrix (#alerts)

CI/CD bot: Status deploymentów, aktualizacji, buildów

Monitoring bot: Alerty z Prometheus/Grafana (np. workload down, threshold exceeded)

Helpdesk bot: Ticketing integration (np. tworzenie ticketów z wiadomości Matrix)

Integracje działają jako dedykowane konta serwisowe (@bot-siem:sylian.example.com) z ograniczonymi uprawnieniami (read/write w dedykowanych pokojach, brak dostępu do DM operatorów).

Bezpieczeństwo integracji: boty komunikują się z homeserverem przez mTLS (Zone 4 → Zone 4). Tokeny botów są przechowywane w Vault. Każda integracja wymaga zatwierdzenia administratora.

39.7. Integracje zewnętrzne

Status: [O] Opcjonalny Odbiorca: Administrator Wpływ na baseline: Średni Powiązane rozdziały: 39.3, 39.6, 40.7

Matrix bridges umożliwiają komunikację z zewnętrznymi platformami:

Bridge	Platforma	Ryzyko	Rekomendacja
mautrix-signal	Signal	Średnie	Opcjonalny (PRO)
mautrix-whatsapp	WhatsApp	Wysokie	Niezalecany
mautrix-telegram	Telegram	Wysokie	Niezalecany
Email bridge	SMTP/IMAP	Średnie	Opcjonalny (powiadomienia)
IRC bridge	IRC	Niskie	Opcjonalny

Ryzyko bridges: Bridges przekazują wiadomości między Matrix (kontrolowany) a zewnętrzną platformą (niekontrolowana). Ryzyko: (a) wyciek danych do niekontrolowanej infrastruktury, (b) zależność od zewnętrznej platformy, (c) bridge jako punkt awarii, (d) niedopasowanie polityk szyfrowania (E2EE Matrix vs. brak E2EE na zewnętrznej platformie).

Dla tieru STATE: bridges zewnętrzne są niedopuszczalne. Komunikacja z podmiotami zewnętrznymi odbywa się przez federację Matrix (39.3) lub przez dedykowany kanał (email szyfrowany PGP/S/MIME).

39.8. Polityki egress Matrix

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 39.3, 38.9, 42.13

Homeserver Matrix ma ściśle zdefiniowane połączenia wychodzące:

Dozwolone: - Federacja: połączenia HTTPS (port 8448) do homeserwerów z allowlist (39.3) - Media download: pobieranie mediów z federacyjnych homeserwerów (przechodzenie przez CDR) - DNS: resolver SYLION (Zone 4) - TURN/STUN: serwer VolP (Zone 4) dla połączeń voice/video

Zablokowane: - Dowolny ruch do internetu poza federacją - Połączenia do IP/domen spoza allowlist - Outgoing webhooks do zewnętrznych URL (jeśli nie zatwierdzone)

Firewall na hoście homeservera: allowlist-based (brak default-allow dla egress).

39.9. Wdrożenia suwerenne (Sovereign Deployments)

Status: [O] Opcjonalny Odbiorca: Architekt, Administrator (STATE) Wpływ na baseline: Wysoki Powiązane rozdziały: 39.1, 39.3, 51.6

Wdrożenie suwerenne (sovereign deployment) oznacza pełny deployment homeservera Matrix na infrastrukturze kontrolowanej przez organizację — bez jakiegokolwiek zależności od zewnętrznych usług chmurowych.

Wymagania: - Homeserver on-premise lub w krajowym datacenter - Brak federacji z zewnętrznymi podmiotami (domyślnie) - Brak zewnętrznych zależności (brak matrix.org, brak identity server, brak integration server) - Pełna kontrola nad kluczami E2EE (cross-signing keys przechowywane w HSM organizacji) - Backup szyfrowany, przechowywany on-premise

Sovereign deployment jest domyślnym trybem dla tieru STATE.

39.10. Dark-Matrix / scenariusze onionowe [O/E]

Status: [O] Opcjonalny / [E] Eksperymentalny Odbiorca: Architekt (R&D), Operacje specjalne Wpływ na baseline: Niski (niezależne od baseline) Powiązane rozdziały: 39.9, 34.12, 51.7

Dark-Matrix to koncepcja homeservera Matrix dostępnego wyłącznie przez sieć onionową (Tor) lub przez dedykowane połączenia VPN — brak publicznego adresu IP, brak widoczności w DNS.

Scenariusze: 1. Onion homeserver: Homeserver dostępny przez adres .onion (Tor hidden service). Klienci Matrix łączą się przez Tor. Korzyść: brak możliwości ustalenia lokalizacji fizycznej homeservera 2. VPN-only homeserver: Homeserver dostępny wyłącznie przez dedykowaną sieć VPN (IPsec). Brak publicznego endpointu 3. Air-gapped homeserver: Homeserver w sieci odizolowanej od internetu. Komunikacja wyłącznie wewnątrz organizacji

Status: Eksperymentalny. Nie objęty baseline. Wymaga dedykowanego R&D i walidacji.

39.11. Ograniczenia, ryzyka i decyzje architektoniczne

Status: [N] Normatywny Odbiorca: Architekt, Decydent Wpływ na baseline: Wysoki Powiązane rozdziały: 39.1–39.10

Ograniczenia Matrix: 1. Wydajność: Synapse jest zasobożerny. Dendrite jest lepszy, ale młodszy 2. E2EE UX: Zarządzanie kluczami E2EE (cross-signing, key backup) jest skomplikowane dla użytkowników nietechnicznych. SYLION musi zapewnić automatyzację (key backup w Vault, automatyczny cross-signing) 3. Federacja i prywatność metadanych: Federacja ujawnia metadane (kto rozmawia z kim, kiedy) homeserwerom federacyjnym. Dla STATE: brak federacji eliminuje ryzyko 4. Media handling: Pliki w Matrix są przechowywane na homeserverze. Integracja z CDR (42.6) jest niezbędna 5. Audit: Matrix nie loguje treści wiadomości (E2EE). Dla celów compliance — rozważenie server-side audit bridge (kontrowersyjne, osłabia E2EE)

Decyzje architektoniczne: | Decyzja | Wybór | Uzasadnienie | —|—|—| Homeserver | Dendrite (PRO/STATE), Synapse (STANDARD) | Wydajność vs. dojrzałość | | E2EE | Domyślne dla DM, opcjonalne dla pokojów | Balans bezpieczeństwa i UX | | Federacja | Allowlist (PRO), brak (STATE) | Kontrola metadanych | | Key backup | Automatyczny, w Vault | UX + bezpieczeństwo | | Media CDR | Obowiązkowy | Ochrona przed malware | | Bridges | Opcjonalne (PRO), zablokowane (STATE) | Kontrola egress |

Rozdział 40. Signal jako workload kompatybilności

40.1. Uzasadnienie kompatybilności

Status: [N] Normatywny Odbiorca: Architekt, Decydent Wpływ na baseline: Średni Powiązane rozdziały: 39.1, 40.2, 40.9

Signal jest obecny w ekosystemie SYLION wyłącznie jako workload kompatybilności — narzędzie umożliwiające operatorom komunikację z kontaktami zewnętrznymi, którzy używają Signal jako swojego komunikatora. Signal NIE jest rdzeniem komunikacyjnym SYLION (tę rolę pełni Matrix — Rozdział 39).

Uzasadnienie obecności Signal: 1. Adopcja: Signal jest najpopularniejszym komunikatorem E2EE wśród osób świadomych bezpieczeństwa (dziennikarze, aktywiści, prawnicy, urzędnicy). Wielu kontaktów operatorów SYLION jest dostępnych wyłącznie przez Signal 2. Reputacja kryptograficzna: Signal Protocol (Double Ratchet) jest złotym standardem E2EE. Operator komunikujący się przez Signal z osobą zewnętrzną ma gwarancję szyfrowania E2E 3. Brak alternatywy: Osoba zewnętrzna nie będzie instalować klienta Matrix wyłącznie do komunikacji z operatorem SYLION. Signal jest common ground

Warunki użycia: Signal jest dopuszczalny wyłącznie do komunikacji z podmiotami zewnętrznymi, które nie są użytkownikami SYLION. Komunikacja wewnątrz organizacji SYLION odbywa się przez Matrix.

40.2. Dlaczego Signal nie jest rdzeniem

Status: [N] Normatywny Odbiorca: Architekt, Decydent Wpływ na baseline: Krytyczny Powiązane rozdziały: 39.1, 40.1, 40.8

Signal nie może być rdzeniem komunikacyjnym SYLION z powodów architektonicznych i operacyjnych:

Centralna infrastruktura: Signal wymaga połączenia z serwerami Signal Foundation (USA). Brak możliwości self-hosting. Dla tieru STATE jest to niedopuszczalne — zależność od podmiotu zagranicznego dla krytycznej funkcji komunikacji

Brak federacji: Signal nie federuje — komunikacja jest możliwa wyłącznie w obrębie ekosystemu Signal. Brak interoperacyjności z innymi protokołami

Identyfikacja numerem telefonu: Signal wymaga numeru telefonu do rejestracji. Numer telefonu: (a) jest PII (personally identifiable information), (b) jest podatny na SIM swap attack, (c) ujawnia przynależność organizacyjną (jeśli numer służbowy)

Brak kontroli organizacyjnej: Administrator SYLION nie ma możliwości: tworzenia pokojów organizacyjnych, zarządzania uprawnieniami, retencji wiadomości, audytu, moderacji — te funkcje nie istnieją w Signal

Brak API: Signal nie oferuje oficjalnego API integracyjnego. Boty, webhooks, integracje z CRM/SIEM — niemożliwe

Ograniczony klient desktopowy: Signal Desktop wymaga sparowania z telefonem — dodatkowa zależność

Jurysdykcja: Signal Foundation podlega prawu USA — potencjalne ryzyko NSL (National Security Letter), FISA Court order

Podsumowanie: Signal jest doskonałym komunikatorem osobistym, ale nie spełnia wymagań platformy korporacyjnej/rządowej. Matrix spełnia te wymagania.

40.3. Model działania w microVM

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 38.4, 40.1, 40.4

Signal działa w SYLION jako izolowany workload (env-signal) — klient Signal Desktop uruchomiony w microVM Firecracker (PRO/STATE) lub rootless container (STANDARD).

Architektura:

[Terminal] ← pixel stream → [Session Broker] ← capture → [env-signal microVM] ↓ [Serwery Signal (internet)] (przez forward proxy Zone 4)

Operator widzi Signal Desktop jako okno streamowane z env-signal. Dane Signal (baza wiadomości, klucze sesji) rezydują w data volume env-signal — nigdy na terminalu operatora.

Konfiguracja microVM env-signal: | Parametr | Wartość | |—| | vCPU | 1 | | RAM | 512 MB | | Rootfs | Alpine Linux + Signal Desktop (Electron) + Xvfb | | Data volume | 1 GB (STANDARD), 2 GB (PRO), 5 GB (STATE) | | Egress | Wyłącznie serwery Signal (allowlist) przez proxy Zone 4 | | Ingress | Brak (wyłącznie Session Broker) |

Sparowanie: Pierwsze uruchomienie wymaga sparowania Signal Desktop z telefonem operatora (QR code scan). W modelu SYLION: (a) operator skanuje QR code wyświetlony w env-signal za pomocą telefonu osobistego (nie terminala SYLION), (b) po sparowaniu — env-signal działa autonomicznie, (c) resparowanie wymagane po rebuild env-signal (jeśli data volume wymazany).

40.4. Polityki egress i dostępu

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 38.9, 40.3, 42.13

env-signal ma ściśle ograniczony egress:

Dozwolone połączenia wychodzące: - Serwery Signal API: chat.signal.org, storage.signal.org, cdn.signal.org, cdn2.signal.org, updates.signal.org (porty 443) - Serwery Signal TURN/STUN: turn.signal.org (porty 443, 3478) - DNS: resolver SYLION (Zone 4)

Zablokowane: - Wszystkie inne połączenia do internetu - Połączenia do innych workloadów operatora - Połączenia do Zone 4 services (poza DNS i proxy)

Forward proxy: Ruch z env-signal do serwerów Signal przechodzi przez forward proxy w Zone 4 (Squid/Envoy). Proxy: (a) weryfikuje destination (allowlist domen Signal), (b) loguje metadane (timestamp, destination, bytes), (c) blokuje próby połączenia do niedozwolonych domen.

Autoupdate: Automatyczne aktualizacje Signal Desktop są zablokowane w env-signal (brak dostępu do updates.signal.org lub kontrolowany — 49.1). Aktualizacja Signal Desktop odbywa się przez pipeline OTA SYLION (49.3) — nowy obraz env-signal z zaktualizowanym Signal.

40.5. Polityki plików i schowka

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 37.9, 37.10, 42.1

Pliki w env-signal: Pliki otrzymane przez Signal (załączniki) są przechowywane w data volume env-signal. Pliki te: - Nie są automatycznie dostępne w innych workloadach operatora - Transfer do innego workloadu wymaga explicit action (copy → staging → CDR → target workload) - Transfer na terminal operatora podlega polityce eksportowej G2 (36.7)

Pliki wysyłane przez Signal (operator → kontakt zewnętrzny): - Operator tworzy/pobiera plik w env-office lub env-browser - Plik przechodzi staging (Zone 4) → CDR → env-signal - Operator wysyła plik przez Signal

Schowek: Clipboard między env-signal a innymi workloadami podlega polityce cross-workload (37.9) — domyślnie zablokowany (STANDARD), dozwolony z limitem (PRO), zablokowany (STATE).

Clipboard między env-signal a terminalem: podlega standardowej polityce clipboard (37.9).

40.6. Monitoring i rebuild

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Średni Powiązane rozdziały: 38.11, 38.14, 40.3

Monitoring env-signal: - Metryki: CPU, RAM, disk I/O, network I/O (per microVM) - Egress monitoring: weryfikacja, że ruch wychodzący trafia wyłącznie na dozwolone domeny (proxy log) - Anomalia: ruch do nieznanego IP → alert HIGH

Rebuild: env-signal jest rebuildowany: (a) automatycznie co 7 dni (rotacja — utrudnienie persistence), (b) na żądanie administratora, (c) w przypadku anomalii.

Rebuild z zachowaniem danych: data volume jest zachowany, nowa microVM montuje istniejący volume. Historia wiadomości i sparowanie są zachowane.

Clean rebuild: data volume wymazany — wymagane ponowne sparowanie z telefonem operatora. Stosowany w przypadku podejrzenia kompromitacji.

40.7. Ograniczenia interoperacyjności

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Niski Powiązane rozdziały: 39.7, 40.1, 40.2

Signal nie oferuje interoperacyjności z innymi protokołami. Ograniczenia: 1. Brak bridge Matrix ↔ Signal na poziomie serwera (mautrix-signal istnieje, ale wymaga klienta Signal — 39.7) 2. Brak API do programowej obsługi wiadomości (boty, automatyzacja) 3. Brak forwarding wiadomości Signal → Matrix bez manualnej akcji operatora 4. Brak wspólnej listy kontaktów Signal ↔ Matrix

Konsekwencja: Operator zarządza dwoma niezależnymi komunikatorami (Matrix w env-matrix, Signal w env-signal). Nie ma automatycznej synchronizacji wiadomości między nimi. To jest celowa decyzja architektoniczna — automatyczna synchronizacja osłabiłaby izolację workloadów.

40.8. Ryzyko zależności od infrastruktury zewnętrznej

Status: [N] Normatywny Odbiorca: Architekt, Decydent Wpływ na baseline: Wysoki Powiązane rozdziały: 40.2, 40.4, 51.3

env-signal jest jedynym workloadem w SYLION z bezpośrednią zależnością od infrastruktury zewnętrznej niekontrolowanej przez SYLION:

Ryzyka: 1. Dostępność: Awaria serwerów Signal Foundation → env-signal niedziałający. SYLION nie ma wpływu na SLA Signal 2. Blokada: Signal jest blokowany w niektórych krajach (Chiny, Iran). Operatorzy w tych lokalizacjach nie mogą używać env-signal 3. Zmiana polityki: Signal Foundation może zmienić Terms of Service, zablokować desktop clients, lub zmienić protokół. SYLION nie ma gwarancji ciągłości 4. Fingerprinting: Ruch do serwerów Signal jest rozpoznawalny (domain-based) — napastnik monitorujący ruch na WAN routera wie, że operator używa Signal 5. Jurisdiction: Serwery Signal w USA — potencjalne ryzyko prawne (NSL, FISA)

Mitigacje: - env-signal jest workloadem opcjonalnym — organizacja może go wyłączyć - Komunikacja wewnętrzna odbywa się przez Matrix (brak zależności od Signal) - Proxy ukrywa źródło ruchu (operator SYLION wygląda jak proxy SYLION, nie jak konkretny operator) - Monitoring dostępności Signal → alert jeśli niedostępny > 15 minut

40.9. Kiedy env-signal jest akceptowalny

Status: [R] Rekomendowany Odbiorca: Decydent, Administrator Wpływ na baseline: Średni Powiązane rozdziały: 40.1, 40.8, 51.1

env-signal jest akceptowalny, gdy: 1. Operator musi komunikować się z kontaktami zewnętrznymi, które używają wyłącznie Signal 2. Organizacja akceptuje ryzyko zależności od infrastruktury Signal Foundation (40.8) 3. Dane wymieniane przez Signal nie są klasyfikowane powyżej poziomu „poufne” (dla STATE: env-signal jest narzędziem komunikacji zewnętrznej, nie wewnętrznej — dane krytyczne nie przechodzą przez Signal) 4. Tier: STANDARD (niezalecany), PRO (dozwolony), STATE (dozwolony z ograniczeniami)

40.10. Kiedy env-signal jest niewystarczający

Status: [R] Rekomendowany Odbiorca: Decydent, Architekt Wpływ na baseline: Średni Powiązane rozdziały: 40.1, 40.9, 39.1

env-signal jest niewystarczający (i nie powinien być używany), gdy: 1. Komunikacja dotyczy danych o najwyższej klasyfikacji (tajne, ściśle tajne) — brak kontroli nad serwerami Signal 2. Wymagana jest audytowalność komunikacji — Signal nie oferuje audytu organizacyjnego 3. Wymagana jest integracja z innymi systemami (CRM, ticketing, SIEM) — brak API 4. Komunikacja jest wyłącznie wewnątrzorganizacyjna — Matrix jest właściwym narzędziem 5. Organizacja działa w lokalizacji, gdzie Signal jest blokowany 6. Organizacja wymaga pełnej suwerenności komunikacyjnej (sovereign mode) — env-signal jest niezgodny

W tych scenariuszach: Matrix (federated lub sovereign) jest jedynym dozwolonym komunikatorem.

Rozdział 41. Voice, video i media plane

41.1. Architektura warstwy głosowej

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 37.1, 39.2, 41.2

Warstwa głosowa (voice layer) w SYLION obsługuje połączenia głosowe i wideo zarówno wewnątrz organizacji (Matrix VoIP), jak i z zewnętrznymi systemami telefonicznymi (SIP gateway).

Architektura:

[Terminal mic/speaker] ←audio→ [Session Broker] ←audio→ [env-voice / env-matrix] ↑ [Media Server (Zone 4)] ↑ [Federacja / SIP / PSTN]

Warstwa głosowa składa się z: 1. Terminal audio: Mikrofon i głośnik terminala — przechwytywane przez klienta sesji i transportowane do Session Broker (37.7) 2. Session Broker audio relay: Broker przekazuje audio między terminalem a workloadem (env-voice lub env-matrix) 3. Application audio: Aplikacja VoIP w workloadzie (Element VoIP, SIP softphone) generuje i odbiera audio 4. Media Server (Zone 4): Serwer mediów (Jitsi Videobridge, FreeSWITCH, lub SRTP relay) obsługujący routing połączeń, konferencje, bridging do PSTN/SIP

Kluczowe rozróżnienie: terminal audio (mikrofon/głośnik fizyczny) jest oddzielone od application audio (dźwięk generowany/odbierany przez aplikację VoIP). Session Broker jest pośrednikiem — łączy terminal audio z workloadem, gdzie działa aplikacja VoIP. Ta separacja umożliwia kontrolę i audyt na granicy.

41.2. Separacja media plane od control plane

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 37.17, 41.1, 41.3

Media plane i control plane w warstwie voice/video muszą być rozdzielone:

Control plane (sygnalizacja): - Protokoły: SIP (RFC 3261), Matrix VoIP signaling (m.call.invite) - Funkcje: ustanawianie, modyfikowanie, kończenie połączeń; negocjacja kodeków; ICE candidate exchange - Transport: TCP/TLS (reliable, encrypted) - Lokalizacja: Zone 4 (SIP registrar/proxy, Matrix homeserver)

Media plane (dane audio/video): - Protokoły: RTP/SRTP (RFC 3550/3711), DTLS-SRTP (WebRTC) - Funkcje: transport audio/video frames - Transport: UDP (unreliable, low latency) - Lokalizacja: Zone 4 (media server) ← relay → workload (Zone 3) ← relay → Session Broker (Zone 3) ← → terminal

Korzyści separacji: 1. Media plane może być skalowany niezależnie (dodawanie media nodes) 2. Control plane może być w innej lokalizacji niż media plane (distributed deployment) 3. Failover control plane nie przerywa media (krótkoterminowo) 4. Różne polityki QoS (34.6) per plane

41.3. Terminal media vs application media

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 41.1, 37.7, 41.7

W architekturze SYLION media audio/video istnieją na dwóch poziomach:

Terminal media: Audio z mikrofonu i do głośnika terminala. Transport: terminal → Session Broker (przez tunel IPsec). Kodek: Opus (37.7). Latencja: < 100 ms E2E (audio only).

Application media: Audio/video generowane przez aplikację VoIP w workloadzie (Element, SIP softphone). Transport: workload → media server (Zone 4). Kodek: Opus (audio), VP8/VP9/H.264 (video). Protokół: WebRTC (DTLS-SRTP).

Łączenie: Session Broker łączy terminal media z application media: - Audio z mikrofonu terminala → Session Broker → PulseAudio/PipeWire w workloadzie → aplikacja VoIP - Audio z aplikacji VoIP → PulseAudio/PipeWire w workloadzie → Session Broker → głośnik terminala

Session Broker nie dekoduje ani nie rekoduje audio (passthrough) — minimalizacja latencji. Wyjątek: jeśli kodeki terminala i workloadu są różne — Session Broker wykonuje transkodowanie (dodatkowa latencja).

41.4. QoS, jitter, packet loss, buforowanie

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 34.6, 41.1, 41.6

Jakość połączeń głosowych i wideo zależy od parametrów sieci:

Progi jakości: | Parametr | Dobra jakość | Akceptowalna | Niedopuszczalna | | Latencja (one-way) | < 75 ms | 75–150 ms | > 150 ms | | Jitter | < 15 ms | 15–30 ms | > 30 ms | | Packet loss | < 1% | 1–3% | > 3% | | Bandwidth (voice) | > 64 kbps | > 32 kbps | < 32 kbps | | Bandwidth (video 720p) | > 1.5 Mbps | > 0.5 Mbps | < 0.5 Mbps |

Bufor dejitter (jitter buffer): Zarówno na terminalu, jak i w workloadzie — adaptacyjny bufor dejitter (20–200 ms). Bufor kompensuje zmienność opóźnień kosztem dodatkowej latencji. Rozmiar bufora jest dynamicznie dostosowywany do aktualnego jitter.

FEC (Forward Error Correction): Opus obsługuje FEC wbudowany (in-band FEC). Dla WebRTC: dodatkowy FEC na poziomie transportu (RFC 5109 — audio, RFC 5956 — video). FEC zwiększa bitrate o 20–50%, ale znacząco poprawia odporność na packet loss.

Adaptacyjny bitrate: Kodek Opus: adaptacyjny bitrate 6–128 kbps. Przy pogorszeniu sieci — automatyczne obniżenie bitrate. Kodek video: adaptacyjny bitrate + obniżenie rozdzielczości/FPS.

QoS (34.6): Ruch voice/video otrzymuje najwyższy priorytet (DSCP EF/AF41) w tunelu IPsec i na routerze.

41.5. Routing połączeń i polityki

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Średni Powiązane rozdziały: 41.1, 41.2, 45.6

Routing połączeń wewnętrznych (Matrix VoIP): Połączenia głosowe/wideo między operatorami tego samego tenanta SYLION są routowane przez media server w Zone 4. Sygnalizacja: Matrix VoIP signaling (homeserver). Media: TURN/STUN server w Zone 4 → DTLS-SRTP.

Routing połączeń federacyjnych (Matrix federation): Połączenia VoIP z operatorami na federacyjnych homeserverach: media przechodzi przez TURN server każdego homeservera. E2EE (Megolm) chroni treść — media serwery nie mają dostępu do plaintext audio/video.

Routing połączeń PSTN/SIP: Opcjonalny moduł SIP gateway (FreeSWITCH / Kamailio) w Zone 4 umożliwia połączenia z publiczną siecią telefoniczną (PSTN) i systemami SIP. Ruch SIP → media server → workload operatora.

Polityki połączeń: | Typ połączenia | STANDARD | PRO | STATE | | VoIP wewnętrzny (Matrix) | Dozwolony | Dozwolony | Dozwolony | | VoIP federacyjny | Dozwolony (allowlist) | Dozwolony (allowlist) | Wymagana polityka | | SIP/PSTN | Niedostępny | Opcjonalny | Dozwolony | | Nagrywanie połączeń | Niedostępne | Opcjonalne (legal recording) | Konfigurowalne |

41.6. Ograniczenia latencji (<150ms E2E dla voice)

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 41.4, 34.13, 37.5

ITU-T G.114 określa maksymalną akceptowalną latencję one-way dla voice na 150 ms. Powyżej 150 ms rozmowa staje się nienaturalna (echo, nakładanie się wypowiedzi).

Budżet latencji w SYLION (one-way):

Segment	Typowa latencja	Max. latencja
Terminal (mikrofon → encode)	5 ms	10 ms
Terminal → router (LAN)	1 ms	5 ms
Router → G1 (tunel IPsec, internet)	15 ms	50 ms
G1 → Session Broker	2 ms	5 ms
Session Broker → workload	1 ms	3 ms
Workload → media server (Zone 4)	2 ms	5 ms
Media server processing	5 ms	10 ms
Media server → remote workload	2 ms	5 ms
SUMA (internal call)	33 ms	93 ms

Dla połączeń wewnętrznych: budżet mieści się w limicie 150 ms nawet w worst case (93 ms one-way).

Dla połączeń federacyjnych: dodatkowa latencja tunelu do zewnętrznego homeservera (15–50 ms). Total: 48–143 ms — nadal w limicie.

Dla połączeń PSTN: dodatkowa latencja SIP gateway + PSTN (20–80 ms). Total: 53–173 ms — może przekraczać limit w worst case. Mitigacja: lokalizacja SIP gateway blisko operatora (same region), optymalizacja routingu PSTN.

Segment krytyczny: Router → G1 (internet). Latencja tego segmentu jest poza kontrolą SYLION. Rekomendacja: łącze o latencji < 30 ms do G1 (fiber, 5G); LTE < 50 ms; Starlink < 60 ms.

41.7. Terminal audio przez broker

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 37.7, 41.1, 41.3

Audio z terminala (mikrofon/głośnik) przechodzi przez Session Broker jako relay. Broker nie analizuje treści audio — passthrough.

Przepływ (voice call): 1. Operator inicjuje połączenie w env-matrix (Element VoIP) lub env-voice (SIP softphone) 2. Sygnalizacja: env-matrix → homeserver (Zone 4) → remote user 3. Media: terminal mikrofon → Opus encode (terminal) → Session Broker → PulseAudio workload → aplikacja VoIP → media server → remote 4. Media return: remote → media server → aplikacja VoIP → PulseAudio workload → Session Broker → terminal głośnik

Session Broker jako relay: Broker transportuje audio jako opaque stream — enkapsulowany Opus frame (lub raw PCM, zależnie od implementacji). Broker: - Nie dekoduje audio (brak dostępu do treści mowy) - Nie rekoduje audio (brak transkodowania — ten sam kodek terminal ↔ workload) - Monitoruje metryki: bitrate, packet loss, latencja - Opcjonalnie: level meter (głośność — do UI, nie do nagrywania)

Wyjątek — Blind Broker [E]: W modelu Blind Broker (37.16) audio jest szyfrowane E2E (terminal ↔ aplikacja VoIP w workloadzie). Broker nie ma dostępu nawet do opaque frames — widzi wyłącznie zaszyfrowane pakiety. Limitacja: brak monitoringu jakości audio na brokerze.

41.8. Application-side media w workloadzie

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Średni Powiązane rozdziały: 41.1, 41.3, 38.4

Aplikacja VoIP w workloadzie (Element, SIP softphone) generuje i odbiera media na poziomie aplikacji:

Audio: Aplikacja korzysta z wirtualnego urządzenia audio (PulseAudio module-pipe-source / module-pipe-sink lub PipeWire equivalent): - Source (mikrofon): Audio z terminala dostarczane przez Session Broker → pipe → aplikacja VoIP widzi wirtualny mikrofon - Sink (głośnik): Audio z aplikacji VoIP → pipe → Session Broker → terminal głośnik

Video (kamera): Jeśli operatorowi jest dozwolone udostępnianie kamery terminala: - Wirtualna kamera w workloadzie (v4l2loopback) - Obraz z kamery terminala: terminal capture → encode → Session Broker → v4l2loopback device w workloadzie → aplikacja VoIP widzi wirtualną kamerę - Domyślnie: kamera wyłączona (polityka sesji)

Wymagania zasobowe: Voice call: dodatkowe ~50 MB RAM (Opus codec + RTP stack). Video call: dodatkowe ~200 MB RAM (VP8/VP9 encode/decode). Workload musi mieć odpowiednie limity zasobów (38.13).

41.9. Sesje konferencyjne

Status: [R] Rekomendowany Odbiorca: Administrator, Architekt Wpływ na baseline: Średni Powiązane rozdziały: 41.1, 41.5, 39.2

Sesje konferencyjne (multi-party voice/video) są obsługiwane przez media server w Zone 4:

Jitsi Videobridge (JVB): Rekomendowany serwer konferencyjny. JVB działa jako Selective Forwarding Unit (SFU) — nie miksują audio/video, lecz selektywnie przekazuje strumienie między uczestnikami. Korzyść: niższe obciążenie serwera, możliwość E2EE per-stream (Insertable Streams).

Architektura konferencji:

[Operator A env-matrix] ↔ [JVB (Zone 4)] ↔ [Operator B env-matrix] ↓ [Operator C env-matrix]

Każdy operator uczestniczy w konferencji z poziomu swojego env-matrix. Media: WebRTC (DTLS-SRTP) z workloadu do JVB.

Limity: | Typ konferencji | Limit uczestników | Tier | |—|—|—| | Audio only | 50 | Wszystkie | | Video (low-res 360p) | 25 | PRO/STATE | | Video (high-res 720p) | 10 | PRO/STATE | | Video (full HD 1080p) | 4 | STATE |

Powyżej limitów: automatyczne przełączenie na audio-only lub obniżenie rozdzielczości.

41.10. Media plane dla trybów suwerennych

Status: [O] Opcjonalny Odbiorca: Architekt (STATE) Wpływ na baseline: Średni Powiązane rozdziały: 39.9, 41.1, 51.6

W trybie suwerennym (sovereign deployment) media plane musi być w pełni kontrolowany:

Media server on-premise (Jitsi Videobridge self-hosted)

Brak TURN/STUN serwerów zewnętrznych (wszystkie on-premise)

Brak wyjścia media do internetu (all-internal)

SRTP z kluczami zarządzanymi przez PKI SYLION (47.3)

Nagrywanie konferencji: opcjonalne, na dedykowanym serwerze on-premise z szyfrowaniem

Tryb suwerenny wyklucza: połączenia PSTN (chyba że SIP gateway on-premise), federację VoIP z zewnętrznymi homeserwerami, TURN relay przez serwery publiczne.

41.11. Blind Broker + SFrame dla audio/video [E]

Status: [E] Eksperymentalny Odbiorca: Architekt (R&D) Wpływ na baseline: Niski (nie w produkcji) Powiązane rozdziały: 37.16, 41.7, 41.12

SFrame (Secure Frame, RFC 9605) umożliwia szyfrowanie poszczególnych ramek audio/video end-to-end — niezależnie od szyfrowania transportowego (DTLS-SRTP). W połączeniu z Blind Broker (37.16) tworzy model, w którym infrastructure nie ma dostępu do treści media.

Koncepcja: 1. Aplikacja VoIP w workloadzie szyfruje każdy frame audio/video kluczem E2EE (SFrame) 2. Zaszyfrowane frames są transportowane przez media server (SFU) — serwer nie może ich odszyfrować 3. Terminal dekoduje po odebraniu — klucz E2EE jest uzgodniony bezpośrednio między uczestnikami

Implementacja: WebRTC Insertable Streams (W3C) + SFrame (RFC 9605). Element Web/Desktop wspiera Insertable Streams (experimental).

Limitacje (RFC 9605 §7.2): - Wymaga obsługi Insertable Streams w kliencie (nie wszystkie przeglądarki/klienty) - Zwiększa zużycie CPU (dodatkowe szyfrowanie per frame) - Utrudnia debugowanie (media server nie widzi treści — nie może diagnozować jakości) - Metadata leakage: rozmiar frames, timing — nadal widoczne dla infrastruktury

41.12. Ograniczenia SFrame (RFC 9605 §7.2)

Status: [E] Eksperymentalny Odbiorca: Architekt (R&D) Wpływ na baseline: Niski Powiązane rozdziały: 41.11, 37.16

RFC 9605 Section 7.2 (Security Considerations) wskazuje na następujące ograniczenia SFrame:

Metadata leakage: SFrame szyfruje treść frames, ale nie ukrywa metadanych: rozmiar frame (korelacja z aktywnością mowy), timing (korelacja z latencją), typ frame (I-frame vs P-frame)

Replay attacks: SFrame counter zapobiega replay, ale wymaga poprawnej implementacji (monotonic counter per sender)

Key management: Wymaga bezpiecznej dystrybucji kluczy między uczestnikami. W SYLION: klucze sesji z MLS (Message Layer Security, RFC 9420) lub dedykowany key server

Rekeying during conference: Zmiana uczestników (join/leave) wymaga rekeying — latency spike

Brak ukrycia aktywności: Aktywność mowy (Voice Activity Detection — VAD) jest widoczna z metadanych nawet przy SFrame

Ocena: SFrame znacząco podnosi bezpieczeństwo media (E2EE per frame), ale nie eliminuje wszystkich wektorów analitycznych. Dla baseline SYLION: DTLS-SRTP jest wystarczające (szyfrowanie hop-by-hop, ale infrastruktura jest trusted). SFrame jest opcją dla scenariuszy o najwyższych wymaganiach (STATE+ / sovereign z zero-trust infrastructure).

41.13. Monitoring jakości mediów

Status: [N] Normatywny Odbiorca: Administrator, SOC Wpływ na baseline: Średni Powiązane rozdziały: 34.13, 41.4, 41.14

Monitoring jakości mediów obejmuje zbieranie metryk w czasie rzeczywistym:

Metryki monitorowane:

Metryka	Źródło	Interwał	Próg alertu
MOS (Mean Opinion Score)	Estimated (E-model)	10 s	< 3.5 (akceptowalny), < 3.0 (zły)
Jitter (audio)	Session Broker	5 s	> 30 ms
Packet loss (audio)	Session Broker	5 s	> 3%
Latency (audio E2E)	Session Broker + terminal	10 s	> 150 ms
Video FPS	Session Broker	5 s	< 15 FPS
Video resolution	Session Broker	event	Drop poniżej 360p
Audio level	Session Broker	1 s	Silence > 30 s (anomalia)

E-model (ITU-T G.107): Estymacja MOS na podstawie parametrów sieci (latencja, jitter, packet loss, kodek). MOS: 1.0 (najgorszy) – 5.0 (najlepszy). Target: MOS > 4.0 (dobra jakość).

Raportowanie: Metryki mediów są raportowane do SIEM/monitoring (Prometheus/Grafana). Dashboard jakości połączeń: per operator, per połączenie, per łącze. Korelacja z metrykami sieci (34.13) umożliwia identyfikację przyczyny degradacji.

41.14. Playbooki degradacji voice/video

Status: [N] Normatywny Odbiorca: Administrator, SOC, Operator Wpływ na baseline: Średni Powiązane rozdziały: 41.13, 34.13, 50.8

Playbooki opisują procedury reagowania na degradację jakości połączeń:

Playbook 1: Wysoki jitter (> 30 ms) 1. Sprawdź metryki sieci (34.13) — router RTT, packet loss 2. Jeśli problem na łączu ISP → sugestia: zmień łącze (LTE → Ethernet, lub odwrotnie) 3. Zwiększ bufor dejitter (do 100 ms) 4. Jeśli problem persist → obniż bitrate audio (Opus 24 kbps)

Playbook 2: Wysoki packet loss (> 3%) 1. Sprawdź metryki sieci — lokalizacja packet loss (router, ISP, wewnętrzny) 2. Włącz FEC (zwiększony bitrate, ale lepsza odporność) 3. Zmiana łącza 4. Jeśli problem wewnętrzny → eskalacja do team infrastruktury

Playbook 3: Wysoka latencja (> 150 ms) 1. Sprawdź budżet latencji (41.6) — który segment jest wąskim gardłem 2. Jeśli internet → zmiana łącza, zmiana lokalizacji G1 (failover na bliższą) 3. Jeśli wewnętrzny → optymalizacja routingu, sprawdź obciążenie media server 4. Jeśli Starlink → akceptacja (latencja inherentna)

Playbook 4: Brak audio (silence) 1. Sprawdź: czy mikrofon terminala jest aktywny (polityka sesji) 2. Sprawdź: czy PulseAudio w workloadzie działa (pipe source/sink connected) 3. Sprawdź: czy Session Broker relay audio (metryki bitrate audio > 0) 4. Restart pipeline audio (Session Broker restart audio relay)

Rozdział 42. Transfer plików, CDR i polityki egress

42.1. Dlaczego transfer plików jest krytyczny

Status: [N] Normatywny Odbiorca: Architekt, Decydent Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.7, 37.10, 42.6

Transfer plików jest jednym z najważniejszych wektorów ataku i jednocześnie niezbędną funkcją operacyjną. Pliki mogą zawierać: (a) malware (exploity, ransomware, backdoor), (b) dane wrażliwe (dokumenty klasyfikowane, dane osobowe), (c) metadane (informacje o autorze, lokalizacji, oprogramowaniu). Każdy plik wchodzący do Zone 3 lub wychodzący z niej jest potencjalnym zagrożeniem.

W architekturze SYLION transfer plików podlega zasadzie: żaden plik nie trafia bezpośrednio do workloadu bez przejścia przez pipeline walidacji i CDR. Jest to mechanizm analogiczny do strefy dezynfekcji — plik jest „dezynfekowany” przed wpuszczeniem do strefy roboczej.

Scenariusze transferu plików w SYLION: 1. Upload z terminala do workloadu: Operator przesyła plik z terminala (np. zdjęcie z Pixela) do env-office 2. Download z workloadu na terminal: Operator pobiera plik z env-office na terminal 3. Transfer przez Matrix: Plik przesłany jako załącznik w wiadomości Matrix 4. Transfer przez przeglądarkę: Plik pobrany z internetu w env-browser 5. Transfer między workloadami: Plik z env-office do env-crm (przez Zone 4) 6. Transfer na zewnątrz: Plik wysłany email/Signal do odbiorcy zewnętrznego

Każdy z tych scenariuszy przechodzi przez odpowiedni pipeline (42.2–42.14).

42.2. Pipeline staging

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.8, 42.1, 42.3

Pipeline staging to sekwencja kroków, przez które plik przechodzi przed dostarczeniem do workloadu docelowego:

[Źródło pliku] → [Staging Area (Zone 2/4)] ↓ [1. Walidacja typu] ↓ [2. Skanowanie AV] ↓ [3. Stripping metadanych] ↓ [4. CDR (rekonstrukcja)] ↓ [5. Kwarantanna (opcjonalna)] ↓ [6. Decyzja polityki] ↓ [Clean staging area] ↓ [Dostarczenie do workloadu]

Staging area: Tymczasowy storage w Zone 2 (dla transferów terminal ↔ workload) lub Zone 4 (dla transferów wewnętrznych i internet): - Szyfrowany at-rest (AES-256) - Retention: max 1 godzina (automatyczne czyszczenie) - Izolowany od workloadów i od siebie (osobna namespace per transfer) - Monitoring: wolumen transferów, wykrywanie anomalii (exfiltration)

Każdy krok pipeline jest logowany z: timestamp, file hash (SHA-256), file type, file size, source, destination, wynik kroku (pass/fail/quarantine).

42.3. Walidacja typu i zgodności

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 42.2, 42.8, 42.4

Pierwszym krokiem pipeline jest walidacja typu pliku — weryfikacja, że deklarowany typ pliku (rozszerzenie, MIME type) odpowiada faktycznej zawartości.

Metody walidacji: 1. Magic bytes (file signature): Sprawdzenie pierwszych bajtów pliku (np. PDF: %PDF, JPEG: FF D8 FF, ZIP: PK). Biblioteka: libmagic (file command) 2. MIME type validation: Porównanie deklarowanego MIME type (nagłówek HTTP, attachment header) z wykrytym (magic bytes) 3. Extension validation: Porównanie rozszerzenia pliku z wykrytym typem. Rozbieżność (np. plik .jpg zawierający PDF) → odrzucenie 4. Deep inspection: Dla kontenerów (ZIP, DOCX, XLSX): weryfikacja struktury wewnętrznej (czy ZIP zawiera oczekiwane pliki, czy DOCX ma poprawny [Content_Types].xml)

Plik odrzucony (type mismatch): Plik z niezgodnym typem → kwarantanna + alert. Operator informowany: „Plik odrzucony — niezgodność typu.”

Lista dozwolonych typów: Administrator definiuje listę dozwolonych typów plików per workload/tier. Przykład: | Typ | STANDARD | PRO | STATE | |---|---|---| | PDF | ✓ | ✓ | ✓ | | DOCX/XLSX/PPTX | ✓ | ✓ | ✓ | | JPEG/PNG/GIF | ✓ | ✓ | ✓ | | ZIP/TAR.GZ | X | ✓ | (po inspekcji) | ✓ | (po inspekcji) | | EXE/DLL/MSI | X | X | X | | JS/VBS/PS1 | X | X | X | | ISO/IMG | X | X | Wymagana dual auth |

42.4. Skanowanie antimalware

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 42.2, 42.3, 42.6

Każdy plik w pipeline jest skanowany przez silnik antimalware:

Silniki: - ClamAV (open source) — bazowy, wymagany we wszystkich tierach - Silnik komercyjny (np. ESET, Sophos, CrowdStrike) — rekomendowany jako drugi silnik (dual-engine scanning) dla PRO/STATE - YARA rules — dodatkowe reguły detekcji (customowe, threat-intel-driven)

Konfiguracja: - Skanowanie: synchroniczne (plik nie przechodzi dalej w pipeline, dopóki skanowanie nie zakończone) - Bazy sygnatur: aktualizowane co 4 godziny (automatycznie) - YARA: aktualizowane przez zespół bezpieczeństwa (manual + threat intel feeds) - Timeout skanowania: 60 sekund per plik. Powyżej: plik odrzucony (timeout → podejrzane)

Wynik skanowania: - Clean: Plik przechodzi dalej w pipeline - Infected: Plik w kwarantannie, alert HIGH w SIEM, operator informowany: „Plik odrzucony — wykryto złośliwe oprogramowanie” - Suspicious: Plik w kwarantannie, alert MEDIUM, wymaga manualnej decyzji administratora - Error: Plik odrzucony (nie można przeskanować — uszkodzony, zaszyfrowany, zbyt duży)

42.5. Stripping metadanych

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 42.2, 42.6, 42.14

Metadane pliku mogą ujawniać informacje wrażliwe: autor, organizacja, wersja oprogramowania, lokalizacja GPS (zdjęcia), historia edycji, komentarze ukryte.

Metadane usuwane: - EXIF (zdjęcia): GPS coordinates, camera model, datetime, orientation - Office (DOCX/XLSX/PPTX): Author, company, revision history, comments, tracked changes, template name - PDF: Author, creator, producer, creation date, modification date, embedded JavaScript - Audio/Video: Recording device, GPS, software

Narzędzia: - mat2 (Metadata Anonymisation Toolkit 2) — open source, obsługuje większość formatów - exiftool — EXIF removal - Custom scripts per format (PDF: qpdf --linearize, DOCX: XML manipulation)

Polityka: Stripping metadanych jest obowiązkowy dla plików wchodzących do Zone 3 (upload) i wychodzących z Zone 3 (download/export). Operator nie może zapobiec usunięciu metadanych.

Wyjątek: pliki, w których metadane są istotne biznesowo (np. zdjęcia z lokalizacją GPS — fotoreportaż). Wyjątek wymaga jawnej polityki per workload i akceptacji ryzyka.

42.6. CDR jako warstwa bazowa

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 42.1, 42.2, 42.5

UWAGA KOSZTOWA: OPSWAT Deep CDR. MetaDefender Core jest produktem komercyjnym z licencją rządu \$50 000–150 000+/rok w zależności od wolumenu przetwarzanych plików. Ten koszt NIE jest uwzględniony w kalkulacji €86/user/mc. Przy 100 operatorach OPSWAT dodaje ~€40–125/user/mc do rzeczywistych kosztów. Alternatywy open-source dla tier STANDARD: DocBleach (Apache 2.0, Java, ograniczony zakres typów plików), Dangerzone (GPL, konwersja przez LibreOffice w sandbox). OPSWAT pozostaje rekomendowany dla PRO i obowiązkowy dla STATE ze względu na certyfikację Common Criteria EAL4+ i pokrycie 200+ typów plików.

CDR (Content Disarm and Reconstruction) jest najważniejszym mechanizmem ochrony przed zagrożeniami plikowymi w SYLION. CDR nie polega na detekcji malware (jak AV) — CDR dekonstruuje plik, usuwa wszelki aktywny content (makra, skrypty, embedded objects, exploit payload) i rekonstruuje plik w czystej formie.

Zasada: CDR zakłada, że każdy plik jest potencjalnie złośliwy. Zamiast szukać złośliwego kodu (detection-based), CDR usuwa wszystko, co nie jest konieczne (prevention-based).

Co CDR usuwa: - Makra VBA (Office): Usunięte bezwarunkowo - JavaScript (PDF): Usunięte - Embedded objects (OLE): Usunięte lub rekonstruowane - Active content (Flash, Java applets): Usunięte - Formuły z external references (Excel): Usunięte lub zastąpione wartościami statycznymi - Hyperlinki: Opcjonalnie: usunięte lub oznaczone - Fonty embedded: Rekonstruowane (usunięcie potencjalnie złośliwych fontów)

Narzędzia CDR: - Open source: DocBleach, Dangerzone (Qubes OS inspired) - Komercyjne: Votiro, OPSWAT MetaDefender, Glasswall - Custom pipeline: LibreOffice conversion (DOCX → PDF → DOCX), ImageMagick reversion (JPEG → BMP → JPEG)

Rekomendacja SYLION: Tier STANDARD: CDR open source (DocBleach + mat2 + custom scripts) Tier PRO: CDR komercyjny (OPSWAT MetaDefender lub Votiro) + open source Tier STATE: Dual CDR (dwa niezależne silniki) + manual review dla plików High-Risk

Ograniczenia CDR: - CDR może zmienić formatowanie pliku (np. fonty, layout) - Pliki zaszyfrowane (password-protected ZIP/PDF) nie mogą przejść CDR → patrz 42.10 - CDR nie obsługuje wszystkich formatów — nieznan format → odrzucenie

42.7. Kwarantanna i decyzja polityki

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 42.4, 42.6, 45.7

Plik, który nie przejdzie walidacji, skanowania AV lub CDR, trafia do kwarantanny:

Kwarantanna: - Izolowany storage w Zone 2/4 — brak dostępu z workloadów - Szyfrowany at-rest - Retention: 30 dni (po tym okresie — automatyczne usunięcie) - Dostęp: wyłącznie administrator bezpieczeństwa (dual auth dla STATE)

Decyzja: 1. Automatyczna: Plik z wykrytym malware (42.4) → permanentne odrzucenie + alert 2. Manualna: Plik podejrzany (suspicious) → administrator bezpieczeństwa analizuje: (a) sandboxing (uruchomienie pliku w izolowanym środowisku), (b) analiza statyczna (strings, hex dump), (c) kontekst (kto przesłał, dlaczego, oczekiwany?) 3. Release: Administrator potwierdza, że plik jest bezpieczny → plik przechodzi resztę pipeline (CDR) i jest dostarczany do workloadu 4. Delete: Administrator potwierdza, że plik jest złośliwy → usunięcie z kwarantanny + powiadomienie operatora

Wszystkie decyzje kwarantanny są logowane w audyt trail.

42.8. Blokada typów plików

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 42.3, 42.6, 45.7

Oprócz listy dozwolonych typów (42.3), SYLION definiuje listę bezwzględnie zablokowanych typów plików:

Blacklist (zablokowane bezwarunkowo): | Typ | Rozszerzenie | Uzasadnienie | |—|—| | Executable (Windows) | .exe, .dll, .msi, .scr, .bat, .cmd, .com | Executables — niedopuszczalne w Thin Client | | Script | .js, .vbs, .wsf, .ps1, .sh, .py | Skrypty — wektor ataku | | Java | .jar, .class | Java — wektor ataku | | Disk image | .iso, .img, .vhd, .vmdk | Image — potencjalny container malware | | Shortcut | .lnk, .url | Shortcut — phishing wektor | | Registry | .reg | Windows registry — nie dotyczy (SYLION nie używa Windows w workloadach domyślnie) | | Archive (nested) | .zip, .tar.gz, .gz | Zagnieżdżone archiwa — patrz 42.9 |

Blacklist jest egzekwowana na etapie walidacji typu (42.3) — przed skanowaniem AV i CDR.

Modyfikacja blacklist wymaga change management + dual auth (STATE). Dodanie wyjątku: jawna akceptacja ryzyka + ograniczenie czasowe.

42.9. Obsługa archiwów

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 42.3, 42.4, 42.6

Archiwa (ZIP, TAR, RAR, 7Z) wymagają specjalnej obsługi — zawierają wiele plików, mogą być zagnieżdżone i mogą ukrywać złośliwą treść.

Procedura obsługi archiwów: 1. Dekompresja w sandbox: Archiwum jest dekompresowane w izolowanym środowisku (kontener lub microVM) 2. Limit zagnieżdżenia: Max. 3 poziomy zagnieżdżenia (ZIP w ZIP w ZIP). Powyżej → odrzucenie 3. Limit rozmiaru: Ratio kompresji > 100:1 → odrzucenie (zip bomb detection) 4. Limit liczby plików: Max. 1000 plików w archiwum. Powyżej → odrzucenie 5. Per-file processing: Każdy plik z archiwum przechodzi pełny pipeline (42.3 → 42.4 → 42.5 → 42.6) 6. Rekonstrukcja: Po przetworzeniu — czysty archiwum jest rekonstruowany z przetworzonymi plikami 7. Wynik: Jeśli choćby jeden plik z archiwum jest odrzucony → całe archiwum w kwarantannie

Zip bomb detection: - Ratio check: rozmiar po dekompresji / rozmiar archiwum > 100 → alert - Recursive check: wielopoziomowe ZIP → limit 3 poziomów - Timeout: dekompresja > 120 sekund → abort + odrzucenie

42.10. Obsługa plików zaszyfrowanych

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 42.6, 42.7, 42.8

Pliki zaszyfrowane (password-protected PDF, encrypted ZIP, PGP-encrypted files) stanowią wyzwanie dla pipeline CDR — nie mogą być zdekompresowane, przeskanowane ani zrekonstruowane bez klucza.

Polityka domyślna: | Typ | STANDARD | PRO | STATE | |—|—|—| | Password-protected ZIP | Odrzucone | Kwarantanna (manual) | Odrzucone | | Password-protected PDF | Odrzucone | Kwarantanna (manual) | Odrzucone | | PGP/GPG encrypted | Odrzucone | Kwarantanna (manual) | Specjalna procedura | | S/MIME encrypted | Odrzucone | Kwarantanna (manual) | Specjalna procedura |

Specjalna procedura (STATE): 1. Plik trafia do kwarantanny 2. Administrator bezpieczeństwa weryfikuje kontekst (nadawca, uzasadnienie) 3. Operator dostarcza hasło/klucz (przez bezpieczny kanał — Matrix E2EE) 4. Administrator deszyfruje plik w izolowanym środowisku 5. Odszyfrowany plik przechodzi pełny pipeline CDR 6. Czysty plik dostarczany do workloadu

Uzasadnienie restrykcji: Zaszyfrowany plik jest „czarną skrzynką” — nie ma możliwości weryfikacji treści bez klucza. Dopuszczenie zaszyfrowanych plików bez inspekcji tworzy dziurę w warstwie CDR. Polityka SYLION: bezpieczeństwo > wygoda.

42.11. Dostarczenie wyłącznie do wyznaczonego workloadu

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 42.2, 36.9, 38.10

Plik po przejściu pipeline CDR jest dostarczany wyłącznie do workloadu docelowego wskazanego przez operatora lub wynikającego z kontekstu:

Upload z terminala: operator wskazuje workload docelowy (np. env-office)

Download z internetu (env-browser): plik pozostaje w env-browser (nie jest automatycznie przenoszony)

Załącznik Matrix: plik trafia do env-matrix

Transfer między workloadami: plik trafia do wskazanego workloadu docelowego

Zasada: Plik nie jest kopiowany do wszystkich workloadów operatora — trafia wyłącznie do jednego, wskazanego. Transfer do innego workloadu wymaga explicit action (i ponownego CDR).

Implementacja: staging area dostarcza plik do konkretnego data volume (38.7) workloadu. Session Broker informuje operatora o dostępności pliku w workloadzie.

42.12. Eksport danych na terminal

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.7, 37.10, 42.1

Eksport pliku z workloadu na terminal operatora jest operacją o najwyższym ryzyku exfiltracji. Procedura:

Operator żąda eksportu pliku z workloadu

Session Broker przechwytuje żądanie → wysyła do G2

G2 ewaluuje export policy (36.7, 45.7)

ALLOW: plik przechodzi pipeline CDR (reverse — usunięcie metadanych, watermarking)

Watermark: plik jest oznaczany (operator_id, timestamp, file hash) — steganografia lub widoczny watermark

Plik jest dostarczany na terminal przez Session Broker (TLS)

Audyt: zdarzenie logowane w SIEM

DLP (Data Loss Prevention): Przed eksportem: opcjonalne skanowanie DLP (keyword detection, regex patterns, ML-based classification). Wykrycie danych wrażliwych (nr PESEL, numery kart, dane medyczne) → blokada eksportu + alert.

Limity eksportu: | Parametr | STANDARD | PRO | STATE | |—|—|—| | Eksport dozwolony | Nie | Tak (ograniczony) | Wyjątki per operator | | Max rozmiar per plik | N/A | 10 MB | 50 MB | | Max eksport per dzień | N/A | 50 MB | 200 MB (z audytem) | | DLP scan | N/A | Wymagany | Wymagany | | Watermark | N/A | Wymagany | Wymagany |

42.13. Egress internetowy z workloadów

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 38.9, 42.1, 45.9

Egress internetowy (ruch z workloadu do internetu) jest kontrolowany i logowany:

Workloady z dozwolonym egress: - env-browser: przez forward proxy (Zone 4), pełny dostęp HTTP/HTTPS z filtracją - env-signal: wyłącznie serwery Signal (allowlist) - env-matrix (federacja): wyłącznie homeservery z allowlist (port 8448) - env-voice (PSTN/SIP): wyłącznie SIP gateway (Zone 4)

Workloady bez egress: - env-office: brak dostępu do internetu (wyłącznie Zone 4 API) - env-crm: brak dostępu do internetu (wyłącznie Zone 4 API)

Forward proxy (Zone 4): Ruch HTTP/HTTPS z env-browser przechodzi przez forward proxy: - URL filtering: blokada kategorii (malware, phishing, C2, adult — konfigurowalnie) - Threat intelligence: blokada domen z listy zagrożeń (aktualizowane co 4h) - Bandwidth limiting: per operator, per workload - Logging: URL, timestamp, bytes, response code — bez treści (HTTPS jest szyfrowane) - TLS inspection: opcjonalne (kontrowersyjne — wymaga MITM proxy certificate w workloadzie)

Monitoring egress: Anomalia egress (nagły wzrost wolumenu, nowa domena docelowa, ruch do IP z listy C2) → alert w SIEM → potencjalny incident (50.1).

42.14. Silnik polityk egress

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.7, 42.12, 45.7

Silnik polityk egress (realizowany przez G2 + OPA/Rego) podejmuje decyzje o każdej operacji eksportowej/egress:

Dane wejściowe:

```
{ "operator": { "id": "op123", "tier": "PRO", "role": "analyst", "device": { "id": "dev456", "compliant": true }, "action": "file_export", "file": { "type": "application/pdf", "size": 2048000, "hash": "sha256:...", "destination": "terminal", "context": { "time": "2026-04-05T14:30:00Z", "risk_score": 25 } }
```

Wynik:


```
{ "decision": "ALLOW", "conditions": [ "cdr_required", "watermark_required", "dlp_scan_required" ], "audit_id": "audit-789" }
```

Polityka jest konfigurowana w OPA/Rego (45.7) i zarządzana przez administratora. Każda zmiana polityki egress podlega change management i jest wersjonowana.

42.15. Audyt transferów i eksportu

Status: [N] Normatywny Odbiorca: Administrator, Audytor Wpływ na baseline: Krytyczny Powiązane rozdziały: 42.2, 42.12, 46.6

Każda operacja transferu pliku i eksportu danych jest logowana w sposób umożliwiający pełny audyt:

Dane logowane per transfer: | Pole | Opis | |—| | transfer_id | Unikalny identyfikator transferu | | timestamp | Czas operacji | | operator_id | Identyfikator operatora | | device_id | Identyfikator terminala | | source_workload | Workload źródłowy | | destination | Terminal / workload docelowy / internet | | file_hash | SHA-256 pliku oryginalnego | | file_hash_post_cdr | SHA-256 pliku po CDR | | file_type | Typ pliku (detected) | | file_size | Rozmiar pliku | | pipeline_steps | Lista kroków pipeline z wynikami | | policy_decision | ALLOW / DENY / QUARANTINE | | policy_version | Wersja polityki | | watermark_id | Identyfikator watermarku (jeśli zastosowany) |

Logi transferów są przechowywane w SIEM: 1 rok (STANDARD/PRO), 5 lat (STATE). Logi są append-only, integrity-chained (hash łańcuchowy).

Raportowanie: dashboard transferów (per operator, per workload, per typ, per dzień). Anomalie: nietypowy wolumen eksportu, eksport poza godzinami pracy, eksport dużych plików → alert.

Rozdział 43. Usługi wspólne i strefa services

43.1. Zakres usług wspólnych

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 38.10, 43.2, 44.1

Zone 4 (shared services) zawiera usługi współdzielone przez wielu operatorów — dostępne z workloadów w Zone 3 przez kontrolowane API. Zone 4 nie jest bezpośrednio dostępna dla terminali ani z internetu.

Usługi w Zone 4: 1. Matrix homeserver — rdzeń komunikacyjny (Rozdział 39) 2. DNS resolver — filtrujący resolver DNS (34.7) 3. Forward proxy — dostęp do internetu z wybranych workloadów (42.13) 4. CDR pipeline — walidacja i rekonstrukcja plików (Rozdział 42) 5. Media server — Jitsi Videobridge dla konferencji (41.9) 6. CRM backend — API CRM dostępne z env-crm (43.3) 7. AI services — modele ML/LLM (43.4) 8. Config/artifact repository — przechowywanie konfiguracji i artefaktów (43.5) 9. Notification service — powiadomienia push/email (43.6) 10. Metadata service — metadane operatorów, workloadów, polityk (43.7) 11. Data services — bazy danych współdzielone (43.8) 12. Auxiliary integrations — integracje z systemami zewnętrznymi (43.9)

Zasada: Usługi w Zone 4 są multi-tenant — obsługują wielu operatorów, ale dane każdego operatora są logicznie izolowane (per-tenant isolation). Operator nie ma dostępu do danych innego operatora, nawet jeśli korzystają z tego samego serwisu.

43.2. API usług

Status: [N] Normatywny Odbiorca: Architekt, Deweloper Wpływ na baseline: Wysoki Powiązane rozdziały: 43.1, 43.10, 34.5

Komunikacja workload ↔ Zone 4 odbywa się wyłącznie przez zdefiniowane API:

Standardy API: - REST API z JSON: dla usług CRUD (CRM, metadata, data services) - gRPC z Protobuf: dla usług o wysokiej wydajności (AI inference, real-time events) - GraphQL: opcjonalnie, dla usług z kompleksowym modelem danych

Wymagania: - Uwierzytelnienie: mTLS + OIDC token (dual auth — certyfikat klienta + bearer token) - Autoryzacja: per-endpoint, per-method, per-tenant (43.10) - Rate limiting: per operator, per workload - Versioning: API versioned (v1, v2) z deprecation policy (min. 6 miesięcy) - Documentation: OpenAPI 3.0 spec per usługa - Error handling: standardowe kody (4xx, 5xx) z deskryptywnym message (bez ujawniania wewnętrznych detali)

Monitoring API: - Latencja per endpoint (p50, p95, p99) - Error rate per endpoint - Request rate per operator - Anomalie: spike w request rate, nietypowe endpointy → alert

43.3. CRM i systemy biznesowe

Status: [R] Rekomendowany Odbiorca: Administrator, Deweloper Wpływ na baseline: Niski Powiązane rozdziały: 43.1, 43.2, 38.4

CRM (Customer Relationship Management) i inne systemy biznesowe działają jako usługi w Zone 4:

Architektura: - Backend CRM (np. SuiteCRM, ERPNext, custom) działa w Zone 4 - Klient CRM (web-based) działa w env-crm (Zone 3) per operator - Komunikacja: env-crm → CRM API (Zone 4) przez mTLS + OIDC

Izolacja danych: CRM jest multi-tenant — każdy operator/zespół ma dostęp wyłącznie do swoich danych (tenant isolation przez RBAC/ABAC na API). Database-level isolation: (a) osobne schema per tenant (rekomendowane), lub (b) row-level security (akceptowalne), lub (c) osobna baza per tenant (STATE).

Integracje: CRM może integrować się z: - Matrix (powiadomienia o nowych leadach, ticketach) - AI services (automatyczna klasyfikacja, analiza sentimentu) - Email (import/eksport — przez CDR)

43.4. Usługi AI

Status: [R] Rekomendowany Odbiorca: Architekt, Administrator Wpływ na baseline: Średni Powiązane rozdziały: 43.1, 48.1, 48.11

Usługi AI w Zone 4 udostępniają modele ML/LLM workloadom operatorów:

Zakres: - LLM inference: Generacja tekstu, tłumaczenie, streszczanie — modele hostowane on-premise (Llama, Mistral) lub przez API zewnętrzne (przez proxy z anonimizacją) - Klasyfikacja: Kategoryzacja wiadomości, ticketów, dokumentów - Anomaly detection: Detekcja anomalii w logach, ruchu sieciowym (48.3) - NLP: Analiza sentimentu, NER (Named Entity Recognition)

Bezpieczeństwo AI (43.4 → 48.11): - Dane przesyłane do modelu AI nie mogą opuszczać infrastruktury SYLION (brak wysyłania do publicznych API LLM bez anonimizacji) - Model poisoning: modele pobierane z zewnątrz muszą być zwalidowane (hash, źródło) - Prompt injection: walidacja inputu przed przekazaniem do LLM - Output sanitization: output LLM jest traktowany jak niezauwany (nie jest bezpośrednio wykonywany)

43.5. Repozytoria konfiguracji i artefaktów

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 43.1, 46.3, 49.6

Zone 4 zawiera repozytoria konfiguracji i artefaktów:

Git repository (internal): - Konfiguracje infrastruktury (Terraform, Ansible) - Polityki OPA/Rego - Pipeline CI/CD definitions - Dokumentacja

Artifact registry: - Obrazy kontenerów (OCI images) - Firmware (router — 33.4) - Obrazy microVM (rootfs — 38.4) - Pakiety klienta SYLION (terminal — 49.1)

Wymagania: - Artefakty podpisywane (Ed25519 lub Sigstore/cosign) - Hash SHA-256 publikowany w manifest - Skanowanie artefaktów (Trivy, Gripe) — vulnerability scanning - Retention policy: latest + 3 previous versions (minimum) - Dostęp: read dla Zone 3 workloadów (pull artifacts), write wyłącznie z Zone 5 (push artifacts)

43.6. Usługi powiadomień

Status: [R] Rekomendowany Odbiorca: Administrator Wpływ na baseline: Niski Powiązane rozdziały: 39.6, 43.1, 50.1

Usługa powiadomień w Zone 4 odpowiada za dostarczanie alertów i notyfikacji:

Kanały powiadomień: - Matrix: Wiadomości w dedykowanych pokojach (#alerts, #operations, #per-team) - Email: Powiadomienia email (SMTP relay w Zone 4) - Push: Opcjonalne push notifications na terminal (przez klienta sesji) - Webhook: Powiadomienia do zewnętrznych systemów (przez forward proxy, kontrolowane)

Typy powiadomień: - Alerty bezpieczeństwa (SIEM → notification service → Matrix/email) - Status operacyjny (deployment, maintenance, incident) - Powiadomienia biznesowe (CRM, ticketing) - Powiadomienia administracyjne (certyfikat wygasa, quota exceeded)

43.7. Usługi metadanych

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Średni Powiązane rozdziały: 43.1, 43.2, 44.1

Usługa metadanych w Zone 4 jest centralnym źródłem informacji o: - Operatorach: ID, tier, rola, przypisane workloady, status - Workloadach: typ, host, status, resource usage - Politykach: aktualna wersja, hash, data ostatniej zmiany - Infrastrukturze: hosty, G1/G2 status, routery status

API metadanych jest read-only dla workloadów (Zone 3). Write wyłącznie z Zone 5 (management).

Caching: workloady mogą cachować metadane (TTL: 60 sekund). Invalidation: push notification przy zmianie (event-driven).

43.8. Usługi danych

Status: [R] Rekomendowany Odbiorca: Architekt, Administrator Wpływ na baseline: Średni Powiązane rozdziały: 43.1, 43.3, 38.7

Usługi danych w Zone 4 obejmują współdzielone bazy danych:

Typy: - PostgreSQL — relacyjna baza danych (CRM, metadata, audit) - Redis — cache (session state G2, tokeny) - MinIO/S3 — object storage (pliki, artefakty, backup) - Elasticsearch — search engine (logi, full-text search)

Izolacja: Per-tenant isolation: osobne schema (PostgreSQL), osobne bucket (MinIO), osobny index (Elasticsearch). Dane operatora A nie są widoczne dla operatora B.

Szyfrowanie: - At-rest: AES-256 (LUKS lub native encryption engine) - In-transit: mTLS (TLS 1.3) - Per-tenant encryption key: klucz przechowywany w Vault (46.5), per-tenant

Backup: Automatyczny backup co 24h (PostgreSQL: pg_dump, MinIO: bucket replication). Retencja: 30 dni (STANDARD/PRO), 90 dni (STATE). Backup szyfrowany (AES-256, klucz w Vault).

43.9. Integracje pomocnicze

Status: [O] Opcjonalny Odbiorca: Administrator Wpływ na baseline: Niski Powiązane rozdziały: 43.1, 39.7, 42.13

Zone 4 może zawierać integracje z zewnętrznymi systemami:

SMTP relay: Wysyłka email z SYLION (np. powiadomienia, raporty)

SMS gateway: Opcjonalny (dla SMS notifications — nie do auth)

LDAP/AD connector: Synchronizacja tożsamości z istniejącym Active Directory

SIEM connector: Eksport logów do zewnętrznego SIEM (jeśli organizacja posiada własny)

Backup target: Replikacja backupu do zewnętrznego storage

Każda integracja zewnętrzna: (a) przechodzi przez firewall Zone 4, (b) jest logowana, (c) wymaga zatwierdzenia administratora, (d) korzysta z mTLS lub VPN.

43.10. Uwierzytelnienie service-to-service (mTLS + OIDC)

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 34.5, 43.2, 47.4

Komunikacja service-to-service w Zone 4 (i między Zone 3 ↔ Zone 4) wymaga dwuskładnikowego uwierzytelnienia:

mTLS (mutual TLS): Każda usługa i każdy workload posiada certyfikat X.509 wystawiony przez wewnętrzną CA SYLION. Przy połączeniu: obie strony weryfikują certyfikat partnera. Certyfikaty krótkoterminowe (24–72h, automatyczna rotacja przez cert-manager).

OIDC token (bearer): Oprócz certyfikatu, każde żądanie API zawiera bearer token OIDC wystawiony przez IdP SYLION. Token zawiera: tożsamość (operator lub service account), rola, scope, tenant. Token jest weryfikowany przez API gateway usługi docelowej.

Dual auth = mTLS + OIDC: Oba mechanizmy muszą być spełnione jednocześnie. mTLS weryfikuje tożsamość na poziomie sieci (kto się łączy), OIDC weryfikuje tożsamość na poziomie aplikacji (kto łączy).

Korzyść: kompromitacja certyfikatu (MiTM) bez ważnego tokena OIDC nie daje dostępu do API. Kompromitacja tokena OIDC bez ważnego certyfikatu nie pozwala na połączenie.

43.11. Granice dostępu operatora do usług wspólnych

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 43.1, 43.10, 36.2

Operator ma dostęp do usług wspólnych (Zone 4) wyłącznie przez swoje workloady — nie ma bezpośredniego dostępu do API Zone 4 z terminala.

Granice: - Operator korzysta z usług Zone 4 pośrednio: np. otwiera stronę w env-browser → env-browser odpytuje forward proxy (Zone 4) - Operator nie może samodzielnie odpytywać API Zone 4 (np. curl do PostgreSQL) — workload nie ma takiego uprawnienia (egress restrict — 38.9) - Wyjątek: env-crm/env-office mają dostęp do konkretnych endpointów API Zone 4 (CRM API, document storage API)

Per-workload API access: | Workload | Dostępne API w Zone 4 | |—| | env-matrix | Matrix homeserver API | | env-browser | Forward proxy (HTTP/HTTPS) | | env-signal | Forward proxy (Signal servers only) | | env-office | Document storage API, CDR API | | env-crm | CRM API, CDR API | | env-voice | Media server API, SIP gateway |

Dostęp jest egzekwowany przez firewall (nftables na hoście workloadu) + API gateway (mTLS + OIDC scope — 43.10).

Rozdział 44. IAM i zarządzanie tożsamością

44.1. Model tożsamości użytkownika

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.2, 39.3, 44.4

Tożsamość użytkownika (operatora) w SYLION jest centralnie zarządzana przez Identity Provider (IdP) rezydujący w Zone 5 (management). IdP jest jedynym źródłem prawdy o tożsamości operatorów.

Identyfikator operatora: Każdy operator posiada unikalny, niezmienny identyfikator: operator_id (format: UUID v4 lub organizacyjny — np. op-00123).

Identyfikator jest niezależny od: imienia/nazwiska, emaila, numeru telefonu — umożliwia pseudonimizację.

Atrybuty tożsamości:

Atrybut	Typ	Źródło	Zmienialny
operator_id	UUID	IdP (auto)	Nie
display_name	string	Administrator	Tak
email	string	Administrator	Tak
phone	string	Administrator	Opcjonalny
tier	enum	Administrator	Tak (change management)
roles	list	Administrator	Tak
tenant_id	UUID	IdP	Nie
status	enum (active, suspended, deactivated)	Administrator	Tak
created_at	timestamp	IdP	Nie
last_auth	timestamp	IdP	Auto
mfa_methods	list	Operator + admin	Tak

Lifecycle tożsamości: Provisioning → Active → (Suspended) → Deactivated → Deleted. Każda zmiana statusu jest logowana. Deactivation nie usuwa danych — retencja zgodna z polityką organizacyjną i RODO.

44.2. Model tożsamości administratora

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 44.1, 44.9, 46.2

Administratorzy SYLION mają odrębny model tożsamości — podlegają dodatkowym zabezpieczeniom:

Zasady: - Konta administracyjne są oddzielone od kont operatorskich — administrator posiada osobne konto operatora (do pracy) i osobne konto administracyjne (do zarządzania) - Konto administracyjne nie jest używane do codziennej pracy — wyłącznie do operacji zarządzania - Konto administracyjne wymaga silniejszego MFA: FIDO2 (biometryczny) + PIN (two-factor, two-channel) - Sesja administracyjna ma krótszy timeout: 15 minut bezczynności - Dostęp administracyjny: wyłącznie z bastion host (Zone 5 — 46.2) — nie z terminala operatorskiego

Konta administracyjne nazwane: Każde konto administracyjne jest przypisane do konkretnej osoby (named account). Brak kont współdzielonych (shared admin). Brak kont generycznych (generic admin).

Break-glass account: Jedno konto awaryjne (break-glass) z najwyższymi uprawnieniami — używane wyłącznie w sytuacjach awaryjnych (46.9). Poświadczenia: przechowywane w sejfie fizycznym (sealed envelope) lub w Vault z dual-custody unlock.

44.3. Model tożsamości usług

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 44.1, 43.10, 47.4

Usługi (services) w SYLION posiadają tożsamości analogiczne do użytkowników — service accounts:

Service account: Każda usługa w Zone 4 i Zone 5 posiada dedykowane konto serwisowe z: - Unikalnym identyfikatorem (np. svc-matrix-homeserver, svc-cdr-pipeline) - Certyfikatem X.509 (mTLS — 43.10) - Tokenem OIDC (client_credentials grant) - Zdefiniowanymi uprawnieniami (scope) — wyłącznie wymagane minimum (least privilege)

Zasady: - Brak interaktywnego logowania na konto serwisowe (nie-human) - Poświadczenia konta serwisowego przechowywane w Vault (46.5) - Rotacja poświadczeń: automatyczna (certyfikaty: 24–72h, tokeny: 1h) - Audyt: użycie konta serwisowego logowane identycznie jak użytkownika

Workload identity: Workloady operatorów (env-*) posiadają tożsamość kontekstową: workload:operator_id:workload_type. Tożsamość jest automatycznie przypisywana przy uruchomieniu workloadu (SPIFFE/SPIRE lub analogiczny system workload identity).

44.4. Tenant, operator, urządzenie, konto serwisowe

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 44.1, 44.3, 36.3

Hierarchia tożsamości w SYLION:

Tenant (organizacja) — Operator (użytkownik) | — Device (terminal) | — Device (terminal 2 — PRO/STATE) — Operator 2 — Service Account — Admin Account

Tenant: Organizacja korzystająca z SYLION. Izolacja per tenant jest bezwzględna — dane jednego tenanta nie są dostępne dla innego. Tenant ma: identyfikator, domenę (np. tenant.sylon.example.com), tier, limit operatorów.

Operator: Użytkownik końcowy tenanta. Przypisany do workloadów, urządzeń, ról. Identyfikowany przez operator_id (unikalny w ramach tenanta).

Device: Terminal operatora. Przypisany do operatora, identyfikowany przez device_id. Operator może mieć wiele urządzeń (limit per tier: STANDARD = 1, PRO = 2, STATE = 3).

Service Account: Konto usługi (non-human). Należy do tenanta. Nie ma przypisanego urządzenia.

Powiązania: - Operator → Device: many-to-many (operator ma wiele urządzeń, urządzenie może być reassigned) - Operator → Workload: many-to-many (mapowanie G2 — 36.3) - Tenant → Operator: one-to-many - Tenant → Service Account: one-to-many

44.5. RBAC (Role-Based Access Control)

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.2, 44.6, 44.8

RBAC jest bazowym modelem kontroli dostępu w SYLION — każdy operator ma przypisaną jedną lub więcej ról definiujących jego uprawnienia.

Role standardowe:

Rola	Opis	Uprawnienia
operator-standard	Operator tieru STANDARD	Dostęp do env-matrix, env-browser, env-office
operator-pro	Operator tieru PRO	Jak standard + env-signal, env-crm, env-voice
operator-state	Operator tieru STATE	Pełny dostęp do wszystkich workloadów
team-lead	Lider zespołu	Jak operator + widoczność metryk zespołu
auditor	Audytorka	Read-only dostęp do logów i raportów

Role administracyjne (44.9):

Rola	Opis
admin-iam	Zarządzanie tożsamościami
admin-infra	Zarządzanie infrastrukturą
admin-security	Zarządzanie politykami bezpieczeństwa
admin-super	Wszystkie uprawnienia admin (dual auth)

Zasady RBAC: - Operator może mieć wiele ról (kumulatywne uprawnienia) - Rola nie może być pusta (musi definiować co najmniej jedno uprawnienie) - Rola jest przypisywana przez admin-iam - Zmiana roli jest logowana w audyt trail - Role are defined in code (version-controlled RBAC definition)

44.6. ABAC (Attribute-Based Access Control)

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 44.5, 44.7, 36.2

ABAC rozszerza RBAC o atrybuty kontekstowe — decyzja dostępu zależy nie tylko od roli, ale także od atrybutów operatora, urządzenia, zasobu i środowiska:

Atrybuty używane w ABAC: | Kategoria | Atrybuty | |—| | Operator | tier, department, location, clearance_level | | Device | compliant, encryption, os_version, last_heartbeat | | Resource | workload_type, sensitivity_level, data_classification | | Environment | time_of_day, risk_score, network_type |

Przykłady reguł ABAC: - Operator z clearance_level=TOP_SECRET może uzyskać dostęp do workloadu z data_classification=TOP_SECRET - Operator z device.compliant=false nie może uzyskać dostępu do żadnego workloadu - Dostęp do env-crm dozwolony wyłącznie w godzinach time_of_day=08:00-18:00 - Operator z risk_score > 80 wymaga dodatkowej re-autentykacji FIDO2

ABAC jest implementowany w silniku OPA/Rego (Rozdział 45) i ewaluowany przez G2 (36.2).

44.7. PBAC (Policy-Based Access Control)

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 44.5, 44.6, 45.1

PBAC jest najwyższym modelem kontroli dostępu w SYLION — łączy RBAC i ABAC z formalnymi politykami wyrażonymi w języku deklaratywnym (Rego — 45.3).

PBAC vs. RBAC/ABAC: - RBAC: „Kto ma dostęp?” (rola) - ABAC: „W jakim kontekście?” (atrybuty) - PBAC: „Na jakich zasadach?” (polityka formalna, wersjonowana, testowalna)

PBAC umożliwia: (a) wyrażenie złożonych reguł (np. „operator z rolą X, atrybutem Y, w kontekście Z, jeśli nie zachodzi warunek W”), (b) wersjonowanie i audyt polityk (kto zmienił, co, kiedy), (c) testowanie polityk (symulacja decyzji — 45.12), (d) regresję polityk (detekcja osłabienia — 36.12).

Szczegóły implementacji PBAC — Rozdział 45.

44.8. Role standardowe

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Średni Powiązane rozdziały: 44.5, 44.9, 36.3

Pełna lista ról standardowych (non-admin) z uprawnieniami:

Rola	Workloady	Export	Clipboard	Print	Conference
operator-standard	matrix, browser, office	Zablokowany	Zablokowany	Zablokowany	Audio only
operator-pro	Wszystkie standard + signal, crm, voice	Po CDR	Ograniczony	Po CDR	Audio + Video
operator-state	Wszystkie	Per polityka	Per polityka	Dual auth	Audio + Video HD
analyst	browser, office, crm	Po CDR + DLP	Ograniczony	Po CDR	Audio
external-liaison	matrix, signal, browser	Zablokowany	Zablokowany	Zablokowany	Audio only

Role mogą być customizowane przez administratora — powyższa lista jest domyślna. Custom roles wymagają definicji w formacie RBAC (JSON/YAML) i załadowania do IdP.

44.9. Role uprzywilejowane

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 44.2, 44.5, 46.10

Role uprzywilejowane (privileged roles) dają dostęp do operacji zarządzania — są ściśle kontrolowane:

Rola	Zakres	Wymagania
admin-iam	Zarządzanie użytkownikami, rolami, MFA	FIDO2, bastion, JIT
admin-infra	Terraform, Ansible, provisioning	FIDO2, bastion, JIT
admin-security	Polityki OPA, SIEM, incident response	FIDO2, bastion, JIT
admin-pki	PKI, certyfikaty, HSM	FIDO2, bastion, dual auth
admin-super	Wszystkie powyższe	FIDO2, bastion, dual auth, break-glass

Kontrola ról uprzywilejowanych: - JIT (Just-In-Time): rola jest aktywowana na żądanie, na ograniczony czas (max. 4 godziny). Po upływie czasu — automatyczna deaktywacja. Operator musi ponownie zażądać (44.13) - JEA (Just Enough Administration): rola daje wyłącznie uprawnienia wymagane do konkretnego zadania (least privilege) - Dual authorization: operacje destrukcyjne (delete, wipe, policy change) wymagają zatwierdzenia przez drugą osobę uprawnioną (46.10) - Audyt: każda operacja z rolą uprzywilejowaną logowana z pełnym kontekstem - Alerty: aktywacja roli uprzywilejowanej → alert INFO w SIEM. Użycie operacji destrukcyjnej → alert WARN

44.10. SSO, OIDC, SAML, LDAP

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 44.1, 36.2, 39.3

SYLION implementuje SSO (Single Sign-On) oparty na protokołach:

OIDC (OpenID Connect) — preferowany: - IdP SYLION (Keycloak, Authentik, lub Zitadel) wystawia tokeny OIDC - Workloady, G2, usługi Zone 4 weryfikują tokeny OIDC (JWT signed by IdP) - Grant types: authorization_code (operatorzy), client_credentials (service accounts) - Token lifetime: access_token 15 minut, refresh_token 8 godzin

Ryzyko komponentu: Keycloak. Keycloak jako centralny Identity Provider jest jednym z najkrytyczniejszych komponentów systemu — kompromitacja Keycloak oznacza potencjalny dostęp do WSZYSTKICH operatorów. Historycznie Keycloak ma 190+ CVE (NVD), co odzwierciedla dużą powierzchnię ataku wynikającą ze złożoności (OIDC, SAML, LDAP, social login, custom themes, admin API). Mitygacje: (1) FIPS mode (BouncyCastle FIPS provider), (2) minimalna konfiguracja (wyłączenie nieużywanych protokołów i providerów), (3) network isolation (Keycloak dostępny tylko z G2 i bastionu), (4) monitoring anomalii (nietyczne logowania, mass token issuance), (5) regularne patching (Keycloak patche w ciągu 48h od publikacji CVE critical), (6) rozważenie alternatyw z mniejszą powierzchnią ataku: ZITADEL (Go, cloud-native, mniej CVE) lub Authentik (Python, self-hosted, prostszy).

SAML 2.0 — interop: Wsparcie SAML 2.0 dla integracji z istniejącym IdP organizacji (np. Azure AD, Okta, ADFS). SYLION IdP działa jako Service Provider (SP) lub Identity Broker.

LDAP/AD — synchronizacja: Synchronizacja tożsamości z istniejącym Active Directory/LDAP (44.12). SYLION nie używa LDAP jako primary auth — LDAP jest źródłem danych (user provisioning), nie protokołem auth.

SSO flow: 1. Operator otwiera klienta sesji na terminalu 2. Klient przekierowuje do IdP SYLION (OIDC authorization endpoint) 3. Operator uwierzytelnia się: hasło + FIDO2 (MFA) 4. IdP wystawia tokeny (access + refresh + id_token) 5. Klient prezentuje access_token do G2 6. G2 weryfikuje token (podpis, issuer, audience, expiry, scopes) 7. G2 podejmuje decyzję admisji (36.4)

44.11. MFA i FIDO2

Status: [N] Normatywny Odbiorca: Administrator, Operator Wpływ na baseline: Krytyczny Powiązane rozdziały: 32.2, 44.10, 47.1

Multi-Factor Authentication (MFA) jest obowiązkowe w SYLION — żaden operator nie może uwierzytelnić się jednym czynnikiem.

Czynniki: | Czynniki | Typ | Przykład | Wymagany | |---|---|---|---| Hasło / PIN | Something you know | Hasło > 12 znaków | Tak (fallback) | | FIDO2 key | Something you have + are | YubiKey Bio, Titan Key | Tak (primary) | | Biometria (FIDO2) | Something you are | Odcisk palca na FIDO2 key | Zintegrowany z FIDO2 | | TOTP |

Something you have | Authenticator app | Opcjonalny (backup) |

FIDO2 jako primary MFA: FIDO2 (WebAuthn + CTAP2) jest preferowanym mechanizmem MFA w SYLION: - Odporny na phishing (origin binding — klucz jest powiązany z domeną IdP) - Odporny na replay (challenge-response) - Biometria lokalna (odcisk palca na kluczu) — weryfikacja „something you are” bez przysyłania danych biometrycznych na serwer - Referencyjny klucz: YubiKey 5 Bio (FIDO2 + biometria), cena: 200 € (w zestawie hardware kit)

Konfiguracja: - Każdy operator musi sparować co najmniej 2 klucze FIDO2 (primary + backup) - Klucz backup przechowywany w bezpiecznym miejscu (domowy sejf lub organizacyjne depozytorium) - Utrata obu kluczy → procedura emergency re-enrollment (44.15)

TOTP jako backup: Opcjonalny — TOTP (Time-based One-Time Password, RFC 6238) może być używany jako backup w przypadku chwilowej niedostępności klucza FIDO2. TOTP nie jest akceptowany jako jedyny czynnik MFA. Dla STATE: TOTP jest niedopuszczalny — wyłącznie FIDO2.

44.12. Provisioning i lifecycle

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 44.1, 44.4, 38.12

Provisioning (tworzenie konta operatora) i lifecycle management:

Onboarding (provisioning): 1. Administrator tworzy konto operatora w IdP (operator_id, display_name, email, tier, roles) 2. System automatycznie: (a) tworzy strefę operatora w Zone 3 (38.1), (b) provisionuje workloady (38.4), (c) tworzy konto Matrix (39.3) 3. Administrator generuje zaproszenie (invitation link) z jednorazowym tokenem 4. Operator rejestruje klucze FIDO2 (primary + backup) 5. Operator rejestruje terminal w MDM (32.4) i aktywuje profil roboczy (32.5) 6. Test połączenia → operator aktywny

Lifecycle events: | Zdarzenie | Akcje | |—| | Role change | Aktualizacja mapowania G2, aktualizacja RBAC | | Tier upgrade | Provisioning dodatkowych workloadów, zmiana limitów | | Tier downgrade | Deprovisioning nadmiarowych workloadów (z grace period) | | Suspension | Blokada dostępu (G2 DENY), aktywne sesje terminowane | | Reactivation | Przywrócenie dostępu, wymagana re-autentykacja | | Deactivation | Blokada permanentna, retencja danych per polityka | | Deletion | Usunięcie konta, wymazanie danych (RODO), unieważnienie kluczy |

Każda zmiana lifecycle jest logowana w audyt trail i wymaga autoryzacji admin-iam.

44.13. JIT/JEA (Just-In-Time / Just Enough Administration)

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 44.9, 46.2, 46.10

JIT i JEA minimalizują ryzyko uprzywilejowanego dostępu:

JIT (Just-In-Time access): Role uprzywilejowane (44.9) nie są przypisane permanentnie — administrator żąda aktywacji roli na określony czas: 1. Administrator żąda aktywacji roli (np. admin-infra) przez portal JIT 2. Żądanie zawiera: uzasadnienie, planowany czas (max. 4 godziny), zakres operacji 3. Żądanie jest automatycznie zatwierdzone (STANDARD/PRO z logowaniem) lub wymaga zatwierdzenia przez drugą osobę (STATE — dual auth) 4. Rola jest aktywowana na żądany czas 5. Po upływie czasu — automatyczna deaktywacja 6. Cały cykl logowany w audyt trail

JEA (Just Enough Administration): JEA ogranicza zakres uprawnień w ramach roli: - admin-infra + JEA = dostęp wyłącznie do operacji Terraform/Ansible na konkretnym zasobie (np. rebuild G1), nie do całej infrastruktury - admin-pki + JEA = wydanie certyfikatu dla konkretnego routera, nie zarządzanie CA root

Implementacja JEA: dynamiczne scope w tokenie OIDC (per-request scope) lub per-operation authorization w OPA/Rego.

44.14. Recertyfikacja dostępu (Access Recertification)

Status: [N] Normatywny Odbiorca: Administrator, Audytor Wpływ na baseline: Średni Powiązane rozdziały: 44.5, 44.8, 46.12

Recertyfikacja dostępu to periodyczny przegląd uprawnień operatorów — weryfikacja, że przypisane role i mapowania są nadal uzasadnione.

Częstotliwość: - STANDARD/PRO: co 180 dni - STATE: co 90 dni - Role uprzywilejowane: co 30 dni

Procedura: 1. System generuje raport per team lead / manager: lista operatorów z rolami i mapowaniami 2. Team lead / manager weryfikuje: czy operator nadal potrzebuje danej roli? Czy mapowania workloadów są aktualne? 3. Zatwierdzone: role utrzymane. Odrzucone: rola usunięta, operator powiadomiony 4.

Niezaweryfikowane w ciągu 14 dni: automatyczne usunięcie roli (safety net) 5. Raport recertyfikacji archiwizowany (audyt trail)

Recertyfikacja jest wymagana przez regulacje (ISO 27001, SOC 2, NIS2) i stanowi dowód audytowy dla kontroli dostępu.

44.15. Emergency re-enrollment (Sealed Recovery Key + dual auth + 15-min window)

Status: [N] Normatywny Odbiorca: Administrator, Operator Wpływ na baseline: Krytyczny Powiązane rozdziały: 44.11, 47.14, 50.1

Emergency re-enrollment to procedura odzyskania dostępu operatora w przypadku utraty obu kluczy FIDO2 lub kompromitacji tożsamości.

Sealed Recovery Key: Przy onboarding operator (lub administrator) generuje Sealed Recovery Key — jednorazowy kod odzyskiwania przechowywany: - W fizycznym sejfie (zalecane: koperta tamper-evident w depozytorium organizacji) - Lub: zaszyfrowany kluczem split-knowledge (administrator + operator — obie strony muszą być obecne) - Lub: w HSM organizacji (STATE)

Procedura emergency re-enrollment:

Operator zgłasza utratę kluczy FIDO2 przez alternatywny kanał (telefon do admin, osobiste stawiennictwo)

Administrator weryfikuje tożsamość operatora: (a) wiedza (pytania weryfikacyjne), (b) fizycznie (jeśli możliwe), (c) potwierdzenie przez managera operatora

Administrator inicjuje procedurę re-enrollment — wymagana dual authorization (dwie uprawnione osoby potwierdzają)

System otwiera 15-minutowe okno re-enrollment

W tym oknie: operator rejestruje nowe klucze FIDO2 (primary + backup)

Po upływie 15 minut okno zamykane automatycznie (nawet jeśli niekompletne)

Sealed Recovery Key jest unieważniony po użyciu — nowy Sealed Recovery Key jest generowany

Wszystkie poprzednie tokeny i sesje operatora są unieważniane

Zdarzenie logowane jako CRITICAL w SIEM

Zabezpieczenia: - 15-minutowe okno: ogranicza window of opportunity dla napastnika - Dual auth: zapobiega social engineering (napastnik musiałby oszukać dwie osoby) - Unieważnienie starych poświadczeń: zapobiega użyciu skradzionych kluczy po re-enrollment - Sealed Recovery Key: jednorazowy — nie może być użyty ponownie

Rozdział 45. Polityki i silnik decyzji

45.1. Model polityk

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.2, 44.7, 45.2

Polityki w SYLION są formalnymi regułami wyrażonymi w języku deklaratywnym, definiującymi decyzje systemu w kontekście kontroli dostępu, eksportu danych, sesji, urządzeń i sieci. Model polityk jest centralny — wszystkie komponenty decyzyjne (G2, Session Broker, CDR pipeline) konsultują silnik polityk.

Architektura:

[G2 / Session Broker / CDR] → [Policy Engine (OPA)] → {ALLOW, DENY, conditions} ↑ [Policy Bundle] (Git → CI/CD → signed bundle)

Zasady: 1. Deklaratywność: Polityki opisują co jest dozwolone, nie jak jest egzekwowane. Silnik decyzji interpretuje politykę 2. Centralizacja: Jedna instancja OPA (lub klastrer) obsługuje wszystkie decyzje. Brak rozproszonych reguł w różnych komponentach 3. Wersjonowanie: Polityki przechowywane w Git, wersjonowane (semver), podpisane 4. Testowalność: Każda polityka ma testy (unit tests) weryfikujące oczekiwane decyzje 5. Audytowalność: Każda zmiana polityki logowana z: kim, co, kiedy, dlaczego

45.2. Język polityk

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 45.1, 45.3, 45.4

SYLION używa języka Rego (OPA — Open Policy Agent) jako podstawowego języka polityk. Rego jest deklaratywnym językiem zaprojektowanym specjalnie do wyrażania polityk kontroli dostępu i decyzji.

Dlaczego Rego / OPA: 1. Open source (Apache 2.0), Cloud Native Computing Foundation (CNCF) graduated project 2. Deklaratywny: Polityki są czytelne i audytowalne 3. Testowalny: wbudowany framework testowy (opa test) 4. Wydajny: Kompilacja polityk do WASM, cache partial evaluation 5. Szeroka adopcja: Kubernetes (Gatekeeper), Envoy, Terraform, Kong, Styra

Alternatywy rozważone: - XACML (45.4): XML-based, zbyt verbose, trudniejszy w utrzymaniu. Nie wybrany - Cedar (AWS): Nowszy, obiecujący, ale mniejsza ekosystem. Monitorowany - Custom DSL: Zbyt duży koszt utrzymania. Odrzucono

45.3. Implementacja OPA/Rego

Status: [N] Normatywny Odbiorca: Architekt, DevOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 45.1, 45.2, 36.2

Deployment: OPA działa jako sidecar lub standalone service w Zone 2/4: - G2 sidecar: OPA jako kontener sidecar obok G2 — minimalna latencja decyzji (< 1 ms) - Shared OPA: Standalone OPA service w Zone 4 dla decyzji CDR, export, service policies - HA: OPA jest stateless — horizontal scale-out, load balanced

Policy bundle: Polityki są pakowane w bundle (tar.gz), podpisane (Ed25519) i dystrybuowane: 1. Polityki w Git repository (Zone 5) 2. CI/CD pipeline: opa test → opa build → sign bundle → push to bundle server 3. OPA periodicznie pobiera bundle (co 30 sekund) lub jest notyfikowany o nowej wersji 4. OPA weryfikuje podpis bundle → łąduje nowe polityki 5. Stare decyzje (cache) są invalidowane

Przykład polityki (access):

```
package sylion.access import future.keywords.if default allow := false allow if { input.operator.status == "active" input.device.compliant == true input.operator.tier == input.workload.required_tier valid_time risk_acceptable } valid_time if { input.context.hour >= 6 input.context.hour <= 22 } risk_acceptable if { input.context.risk_score < 70 }
```

45.4. XACML i alternatywy

Status: [R] Rekomendowany Odbiorca: Architekt Wpływ na baseline: Niski Powiązane rozdziały: 45.2, 45.3

XACML (eXtensible Access Control Markup Language) jest standardem OASIS dla kontroli dostępu. W SYLION XACML nie jest używany jako primary policy language (Rego jest preferowany), ale może być stosowany w scenariuszach interoperacyjności:

Integracja z istniejącym IAM organizacji opartym na XACML

Eksport polityk SYLION do formatu XACML (dla audytu przez zewnętrzne narzędzia)

Import polityk z systemów XACML (konwersja XACML → Rego)

Konwersja XACML ↔ Rego nie jest trywialna — wymagana jest warstwa translacji. Narzędzia: custom transformer lub manual mapping.

45.5. PBAC i decyzje kontekstowe

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 44.7, 45.1, 45.3

PBAC w SYLION oznacza, że decyzje są kontekstowe — nie statyczne. Ten sam operator z tą samą rolą może otrzymać różne decyzje w zależności od kontekstu:

Dane kontekstowe (input do OPA): | Kategoria | Przykładowe dane | |—| | Tożsamość | operator_id, roles, tier, department | | Urządzenie | device_id, compliant, os_version, encryption, fido2 | | Workload | workload_type, sensitivity, data_classification | | Czas | hour, day_of_week, is_holiday | | Lokalizacja | geo_location (GPS), ip_geolocation, network_type | | Ryzyko | risk_score (SIEM), active_alerts, anomaly_flags | | Sesja | session_duration, session_count, last_auth |

Decyzja jest ewaluowana przy każdym żądaniu (real-time) z aktualnym kontekstem.

45.6. Polityki dostępu

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.2, 36.4, 44.5

Polityki dostępu definiują, kto i kiedy może uzyskać sesję do workloadu:

```
package sylion.access.workload allow_workload(workload) if { operator_active device_compliant tier_matches(workload) time_allowed(workload) risk_acceptable session_limit_not_exceeded }
```

Kluczowe reguły: - operator_active: status operatora = "active" (nie suspended/deactivated) - device_compliant: terminal spełnia baseline (32.14) - tier_matches: tier operatora >= tier wymagany przez workload - time_allowed: opcjonalne ograniczenie czasowe per workload - risk_acceptable: risk score < threshold - session_limit_not_exceeded: operator nie przekroczył limitu sesji

45.7. Polityki eksportowe

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 36.7, 42.14, 45.6

Polityki eksportowe kontrolują wyciek danych z workloadów:

```
package sylion.export default allow_export := false allow_export if { input.action == "file_download" input.operator.tier == "PRO" input.file.size <= 10485760 # 10 MB input.file.type in allowed_types not dlp_flagged cdr_passed } allowed_types := { "application/pdf", "image/jpeg", "image/png", "application/vnd.openxmlformats-officedocument.wordprocessingml.document" } dlp_flagged if { input.dlp_scan.sensitive_data_found == true } cdr_passed if { input.cdr_result.status == "clean" }
```

Polityki eksportowe per tier — patrz 36.7 i 42.12.

45.8. Polityki urządzeń

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 32.14, 36.5, 45.6

Polityki urządzeń definiują wymagania baseline per tier (32.14) w formacie OPA/Rego:

```
package sylion.device device_compliant if { input.device.encrypted == true input.device.secure_boot == true input.device.mdm_enrolled == true input.device.fido2_paired == true input.device.usb_debug_disabled == true heartbeat_fresh os_patch_current } heartbeat_fresh if { time.now_ns() - input.device.last_heartbeat_ns < 300000000000 # 5 minutes } os_patch_current if { input.operator.tier == "STANDARD" } # STANDARD: rekomendowane, nie wymagane os_patch_current if { input.operator.tier in { "PRO", "STATE" } time.now_ns() - input.device.os_patch_date_ns < 2592000000000 # 72 hours }
```

45.9. Polityki sieciowe

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 38.9, 42.13, 34.7

Polityki sieciowe definiują dozwolony egress per workload (38.9) i per operator:

Polityki sieciowe są egzekwowane na dwóch poziomach: 1. Firewall (nftables): Per-workload reguły na hoście (low-level, packet-based) 2. OPA/Rego: Per-workload polityka (high-level, decision-based) — G2 konsultuje OPA przy decyzji o dozwolonym egress

Polityki sieciowe obejmują: allowlist domen per workload, rate limiting per operator, bandwidth caps, protocol restrictions.

45.10. Polityki czasowe i ryzyka

Status: [R] Rekomendowany Odbiorca: Administrator Wpływ na baseline: Średni Powiązane rozdziały: 45.5, 45.6, 50.1

Polityki czasowe: - Ograniczenie godzin pracy (np. 06:00–22:00 — domyślne, konfigurowane per organizacja) - Ograniczenie dni (np. brak dostępu w weekendy — opcjonalne) - Ograniczenie per workload (np. env-crm dostępny wyłącznie w godzinach pracy)

Polityki ryzyka: - Risk score > 50 → wymagana re-autentykacja FIDO2 - Risk score > 70 → DENY (operator kontaktuje SOC) - Risk score > 90 → natychmiastowe terminowanie wszystkich sesji + alert CRITICAL

Risk score jest obliczany przez SIEM na podstawie: anomalii logowania, anomalii egress, anomalii device posture, external threat intelligence.

45.11. Polityki sesji

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 32.11, 37.8, 36.4

Polityki sesji kontrolują parametry aktywnej sesji:

Parametr	STANDARD	PRO	STATE
Max. czas sesji	12h	12h	8h
Re-auth interwał	8h	4h	2h
Bezczynność → re-auth	15 min	15 min	10 min
Bezczynność → zamknięcie	30 min	30 min	20 min
Max. jednoczesne sesje	1	2	3
Heartbeat timeout	5 min	5 min	3 min

45.12. Symulacja polityk

Status: [R] Rekomendowany Odbiorca: Administrator, DevOps Wpływ na baseline: Średni Powiązane rozdziały: 45.1, 45.3, 45.13

Przed wdrożeniem nowej polityki administrator powinien przeprowadzić symulację — weryfikację, jak nowa polityka wpłynie na istniejących operatorów.

Narzędzia: - opa eval — ewaluacja polityki z syntetycznym inputem - opa test — testy jednostkowe polityk - Dry-run mode: G2 ewaluuje nową politykę równolegle z aktualną (shadow mode). Wyniki porównywane — różnice logowane bez wpływu na operatorów - Impact analysis: Skrypt porównujący decyzje aktualnej vs. nowej

polityki dla wszystkich aktywnych operatorów (snapshot stanu)

Procedura: 1. Nowa polityka → testy (opa test) 2. Impact analysis → raport z listą operatorów, których decyzje się zmieniają 3. Review przez zespół bezpieczeństwa 4. Dry-run (shadow mode) przez 24h 5. Jeśli brak anomalii → deploy na produkcję 6. Monitoring przez 48h → rollback jeśli problemy

45.13. Testowanie polityk

Status: [N] Normatywny Odbiorca: DevOps, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 45.3, 45.12, 45.14

Każda polityka OPA/Rego musi mieć testy:

```
package sylion.access_test import future.keywords.if test_allow_active_compliant_operator if { allow with input as { "operator": {"status": "active", "tier": "PRO"}, "device": {"compliant": true, "encryption_enabled": true}, "context": {"hour": 10, "risk_score": 25} } } test_deny_suspended_operator if { not allow with input as { "operator": {"status": "suspended", "tier": "PRO"}, "device": {"compliant": true}, "context": {"hour": 10, "risk_score": 25} } } test_deny_non_compliant_device if { not allow with input as { "operator": {"status": "active", "tier": "PRO"}, "device": {"compliant": false}, "context": {"hour": 10, "risk_score": 25} } }
```

Wymagania: - Minimum 80% code coverage (polityki Rego) - Testy pozytywne i negatywne (ALLOW i DENY) - Testy edge cases (graniczne wartości: risk_score = 69 vs. 70) - Testy regresji (każdy bug → nowy test) - CI/CD: testy uruchamiane automatycznie przy każdym commit do repo polityk

45.14. Audyt zmian polityk

Status: [N] Normatywny Odbiorca: Administrator, Audytor Wpływ na baseline: Krytyczny Powiązane rozdziały: 45.1, 45.13, 46.8

Każda zmiana polityki jest logowana w sposób zapewniający pełną rozliczalność:

Dane logowane: - Kto zmienił (admin_id — named account) - Co zmienił (diff polityki — before/after) - Kiedy zmienił (timestamp) - Dlaczego zmienił (komentarz commit / uzasadnienie change request) - Wersja polityki (semver) - Hash polityki (SHA-256) - Kto zatwierdził (STATE: dual auth — approver_id) - Wynik testów (pass/fail) - Wynik symulacji (impact analysis summary)

Logi zmian polityk są append-only i integrity-chained. Przechowywane: 5 lat (wszystkie tiery).

45.15. Governance polityk

Status: [N] Normatywny Odbiorca: Administrator, Decydent Wpływ na baseline: Wysoki Powiązane rozdziały: 45.1, 45.14, 46.8

Governance polityk to ramowy proces zarządzania politykami:

Ownership: Każda polityka ma właściciela (team/person) odpowiedzialnego za utrzymanie

Review cycle: Przegląd polityk co 90 dni (STATE) lub 180 dni (STANDARD/PRO)

Change process: Zmiana polityki = change request → review → test → simulate → approve → deploy

Exception process: Wyjątek od polityki = exception request → risk assessment → time-limited approval → monitoring → review

Sunset policy: Polityki nieużywane > 180 dni → review, potencjalna archiwizacja

Compliance mapping: Każda polityka jest mapowana na wymaganie regulacyjne (ISO 27001 control, NIS2 artykuł, RODO)

Rozdział 46. Management plane, automatyzacja i strefa administracyjna

46.1. Rola management plane

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 35.1, 36.1, 47.1

Management plane (Zone 5) jest strefą administracyjną SYLION — zawiera narzędzia zarządzania, automatyzacji, monitoringu i kontroli nad całą infrastrukturą. Zone 5 jest najbardziej uprzywilejowaną strefą — kompromitacja Zone 5 oznacza potencjalną kompromitację całego systemu.

Komponenty Zone 5: - Bastion host (46.2) — jedyny punkt wejścia dla administratorów - Automation engine (Terraform + Ansible — 46.3) - Secrets management (HashiCorp Vault — 46.5) - SIEM / monitoring (46.6) - Backup controller (46.7) - IdP (Keycloak/Authentik — 44.10) - Git repository (polityki, konfiguracje, IaC) - PKI / CA (Rozdział 47)

Izolacja Zone 5: - Zone 5 nie jest dostępna z internetu (żaden publiczny endpoint) - Dostęp: wyłącznie przez bastion host (46.2) - Ruch z Zone 5 → inne zone: dozwolony (management) - Ruch z innych zone → Zone 5: ograniczony (telemetria, logi, healthcheck)

46.2. Bastion i dostęp administracyjny

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 44.2, 44.9, 46.1

Bastion host jest jedynym punktem wejścia do Zone 5. Wszystkie operacje administracyjne przechodzą przez bastion.

Architektura:

[Admin terminal] → [VPN/IPsec] → [Bastion Host (Zone 5)] → [Infrastruktura]

Wymagania bastion: - Hardened Linux (immutable rootfs, minimal packages) - Uwierzytelnienie: FIDO2 + OIDC (admin account — 44.2) - Session recording: każda sesja SSH/terminal jest nagrywana (screen recording + command log). Nagrania przechowywane 1 rok - Timeout sesji: 15 minut bezczynności - Brak persistent storage (stateless — po zakończeniu sesji nic nie pozostaje) - Audit: wszystkie polecenia logowane w SIEM - Rate limiting: max. 2 jednoczesne sesje administracyjne - IP allowlist: dostęp wyłącznie z autoryzowanych adresów IP (VPN SYLION admin)

Multi-bastion: Dla HA: dwa bastion hosts (active-active lub active-passive). Oba identycznie skonfigurowane.

46.3. Silnik automatyzacji (Terraform + Ansible)

Status: [N] Normatywny Odbiorca: Administrator, DevOps Wpływ na baseline: Wysoki Powiązane rozdziały: 46.1, 46.4, 49.3

Infrastruktura SYLION jest zarządzana jako kod (Infrastructure as Code — IaC):

Terraform: - Provisioning infrastruktury chmurowej: VM/instancje, sieci, storage, load balancery, DNS - State: przechowywany w encrypted backend (S3 + DynamoDB lock, lub Terraform Cloud) - Modules: reusable modules per komponent (G1, G2, Session Broker, workload host) - Plan review: każdy terraform plan jest reviewowany przed terraform apply

Ansible: - Konfiguracja komponentów: instalacja pakietów, konfiguracja strongSwan, nftables, monitoring - Playbooks: per komponent (router, G1, G2, Session Broker, workload host, bastion) - Inventory: dynamiczny (z Terraform output lub cloud provider API) - Secrets: z Vault (Ansible Vault + HashiCorp Vault integration)

CI/CD: Pipeline (GitLab CI / GitHub Actions): 1. Commit do repo IaC → trigger pipeline 2. Lint + validate (Terraform validate, Ansible lint) 3. Plan (Terraform plan) → human review 4. Apply (po approval) → monitoring 5. Post-deploy tests (smoke tests, healthchecks)

Operacje automatyzacji są logowane w audyt trail. Ręczne zmiany infrastruktury (poza Terraform/Ansible) są wykrywane przez drift detection i flagowane.

46.4. Provisioning/deprovisioning

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 44.12, 38.12, 46.3

Provisioning i deprovisioning operatorów i infrastruktury:

Provisioning operatora: Automatyczny pipeline (Ansible playbook triggerowany przez IAM event): 1. IAM: nowe konto operatora → event 2. Ansible: tworzenie namespace/microVM per workload (38.1, 38.4) 3. Ansible: provisioning storage, konfiguracja egress, deploy rootfs 4. Vault: generowanie kluczy per workload, per operator 5. G2: aktualizacja mapowania operator → workloady 6. Matrix: tworzenie konta na homeserverze 7. Healthcheck → operator gotowy

Deprovisioning operatora: 1. IAM: deactivation konta → event 2. G2: zamknięcie aktywnych sesji 3. Ansible: zatrzymanie workloadów 4. Storage: retention/delete per polityka (RODO) 5. Vault: unieważnienie kluczy 6. Matrix: deactivation konta (retencja wiadomości per polityka) 7. Asset Inventory: oznaczenie terminali jako unassigned

Czas provisioning: < 10 minut (pełna automatyzacja). Czas deprovisioning: < 5 minut.

46.5. Zarządzanie sekretami (OpenBao / HashiCorp Vault)

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 47.1, 46.1, 38.7

HashiCorp Vault / OpenBao (lub równoważny system — np. CyberArk Conjur) jest centralnym systemem zarządzania sekretami w SYLION.

Sekrety zarządzane przez Vault: - Klucze szyfrujące per-tenant (storage encryption — 38.7) - Klucze szyfrujące per-workload - Poświadczenia baz danych (PostgreSQL, Redis) - Tokeny API (integracje, boty) - Certyfikaty TLS (krótkoterminowe — PKI engine) - Klucze SSH (bastion, routery) - Sealed Recovery Keys (44.15)

Architektura Vault: - Vault server w Zone 5 (HA cluster: 3 nodes, Raft consensus) - Seal: auto-unseal przez cloud KMS (AWS KMS, Azure Key Vault) lub HSM (STATE) - Auth methods: AppRole (workloady), OIDC (administratorzy), TLS cert (usługi) - Policies: per-path, per-role — least privilege - Audit: każdy dostęp do sekretu logowany (who, what, when)

Rotacja sekretów: Vault Dynamic Secrets: poświadczenia baz danych i tokeny API są generowane on-demand z krótkim TTL (1–24h) i automatycznie unieważniane po wygaśnięciu. Brak statycznych poświadczeń.

Backup Vault: Snapshot Vault co 4h, szyfrowany, przechowywany w oddzielnej lokalizacji. Restore przetestowany co 90 dni.

46.6. SIEM i monitoring

Status: [N] Normatywny Odbiorca: Administrator, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 46.1, 50.1, 35.6

SIEM (Security Information and Event Management) w Zone 5 zbiera, koreluje i analizuje logi ze wszystkich komponentów SYLION.

Architektura:

[Komponenty SYLION] → [Log collector (Fluentd/Vector)] → [SIEM (Wazuh/ELK/Splunk)] ↓ [Alert engine] ↓ [SOC dashboard] [Notification service]

Źródła logów: - G1: IKE logs, firewall logs, NetFlow - G2: decyzje admisji, export decisions, policy changes - Session Broker: sesje, clipboard, print, screen capture attempts - Workloady: metryki, egress logs, anomalie - Router: config hash, heartbeat, tunel status - MDM: device posture, compliance changes - IAM/IdP: auth events, MFA events, provisioning events - Vault: secret access, policy changes - Infrastructure: system metrics, Terraform/Ansible operations

Monitoring (Prometheus + Grafana): - Metryki infrastrukturalne: CPU, RAM, disk, network per komponent - Metryki aplikacyjne: sesje aktywne, latencja, error rate - Metryki bezpieczeństwa: failed auth attempts, policy denials, certificate expiry - Dashboardy: per komponent, per tier, per operator (anonimizowany)

Alerting: Reguły alertów: per metryka, per log pattern. Integracja z notification service (43.6). Eskalacja: SIEM → Matrix (#alerts) → SOC → admin on-call.

46.7. Kontrola backup

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 43.8, 46.5, 38.7

Backup w SYLION obejmuje: dane operatorów (storage workloadów), konfigurację (IaC, polityki), sekrety (Vault), logi (SIEM).

Polityka backup: | Komponent | Częstotliwość | Retencja | Szyfrowanie | |---|---| | Workload data volumes | Co 24h (incremental), co 7 dni (full) | 30 dni (STANDARD/PRO), 90 dni (STATE) | AES-256, klucz w Vault | | PostgreSQL (Zone 4) | Co 24h (pg_dump) | 30 dni | AES-256 | | Vault snapshot | Co 4h | 30 dni | AES-256 (seal key) | | Git repo (IaC, policies) | Continuous (Git push) | Unlimited (Git history) | At-rest encryption | | SIEM logs | Continuous (retention) | 1 rok (STANDARD/PRO), 5 lat (STATE) | AES-256 |

Backup target: - Primary: object storage (MinIO/S3) w Zone 5 - DR: replikacja do drugiej lokalizacji (cross-region) - STATE: opcjonalnie: air-gapped backup (tape/offline storage)

Restore testing: Testy odtwarzania co 90 dni: (a) pełny restore workloadu operatora, (b) restore bazy danych, (c) restore Vault. Raport z testu archiwizowany.

46.8. Change management

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 45.14, 46.3, 46.10

Każda zmiana w infrastrukturze, konfiguracji lub politykach SYLION podlega procesowi change management:

Typy zmian: | Typ | Przykład | Approval | |—|—| | Standard (pre-approved) | Rotacja certyfikatu, aktualizacja AV baz | Automatyczny (pipeline) | | Normal | Nowa polityka, nowy router model, upgrade komponentu | Review + approval | | Emergency | Hotfix bezpieczeństwa, incident response | Post-hoc approval (48h) |

Przepływ (Normal change): 1. Wniosek (change request): opis zmiany, uzasadnienie, impact analysis, rollback plan 2. Review: zespół bezpieczeństwa, zespół infrastruktury 3. Approval: admin-security lub admin-super (STATE: dual auth — 46.10) 4. Implementation: Terraform/Ansible w pipeline CI/CD 5. Verification: post-deploy tests, monitoring 6. Close: dokumentacja, lessons learned

Tracking: Zmiany trackowane w systemie ticketowym (Jira, GitLab Issues, lub dedykowany) z pełnym audyt trail.

46.9. Freeze / maintenance / break-glass

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 46.8, 44.2, 50.1

Freeze (change freeze): Okres, w którym zmiany są zablokowane (poza emergency). Stosowany: przed ważnymi wydarzeniami (konferencja, audyt), w okresach wysokiego ryzyka (święta).

Maintenance window: Planowany okres na zmiany wymagające downtime: - Informacja z wyprzedzeniem: 72h (STANDARD/PRO), 7 dni (STATE) - Czas: poza godzinami pracy (02:00–06:00 czasu lokalnego operatorów) - Komunikacja: email + Matrix + status page

Break-glass: Procedura awaryjnego dostępu z najwyższymi uprawnieniami (44.2): 1. Administrator uzyskuje break-glass credentials (sealed envelope lub Vault dual-custody) 2. Loguje się na bastion z break-glass account 3. Wykonuje operację awaryjną 4. Sesja jest nagrywana 5. Post-incident: review sesji break-glass, raport, ponowne zapiecztowanie credentials 6. Break-glass credentials rotowane po każdym użyciu

46.10. Dual authorization (Four-Eyes Principle)

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 44.9, 46.8, 47.14

Dual authorization (zasada czterech oczu) wymaga zatwierdzenia operacji przez dwie niezależne uprawnione osoby. Obowiązkowa dla:

Operacje wymagające dual auth: | Operacja | STANDARD | PRO | STATE | |—|—|—| | Remote wipe (full) | Dual auth | Dual auth | Dual auth | | Policy change (osłabiająca) | Nie | Rekomendowane | Dual auth | | Break-glass access | Dual auth | Dual auth | Dual auth | | PKI key ceremony | N/A | N/A | Dual auth | | Emergency re-enrollment | Dual auth | Dual auth | Dual auth | | Operator deactivation | Nie | Nie | Dual auth | | Whitelist modification (STATE) | N/A | N/A | Dual auth |

Implementacja: - Portal dual auth: administrator A inicjuje operację → system wysłał żądanie do administratora B → B zatwierdza (FIDO2 auth) → operacja wykonana - Timeout: żądanie dual auth wygasa po 30 minutach - Audit: obie tożsamości logowane (initiator + approver) - Conflict of interest: administrator nie może zatwierdzić własnego żądania

46.11. JIT admin access

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 44.13, 46.2, 44.9

Patrz 44.13 (JIT/JEA). Podsumowanie dla kontekstu management plane:

Role admin-* nie są permanentnie aktywne

Administrator żąda aktywacji roli na ograniczony czas (max. 4h)

Żądanie logowane, zatwierdzane (automatycznie dla STANDARD/PRO, dual auth dla STATE)

Po upływie czasu: automatyczna deaktywacja

Monitoring: aktywne sesje administracyjne wyświetlane na dashboardzie SOC

46.12. Audyt trail operacji administracyjnych

Status: [N] Normatywny Odbiorca: Administrator, Audytor Wpływ na baseline: Krytyczny Powiązane rozdziały: 46.6, 46.8, 46.10

Wszystkie operacje administracyjne są logowane w sposób umożliwiający pełny audyt:

Dane logowane per operacja: - admin_id (named account) - operation (CREATE/READ/UPDATE/DELETE + resource) - resource_id (co zostało zmienione) - before_state / after_state (diff) - timestamp - source (bastion IP, session ID) - approval (dual auth: approver_id, jeśli wymagane) - JIT session (session_id, granted_role, TTL)

Logi: append-only, integrity-chained (SHA-256). Przechowywanie: 5 lat (wszystkie tiery). Dostęp do logów: read-only dla audytorów (rola auditor — 44.8).

46.13. Rebuild management plane

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 46.1, 46.3, 46.5

Management plane (Zone 5) jest rebuildowalny od zera:

Procedura rebuild: 1. Provisioning infrastruktury Zone 5 (Terraform — z backup state) 2. Deploy komponentów (Ansible) 3. Restore Vault (z backup snapshot) 4. Restore Git repositories (z remote origin) 5. Restore SIEM data (z backup) 6. Rekonfiguracja bastion, monitoring, IdP 7. Healthcheck → Zone 5 operacyjna

Czas rebuild: < 2 godziny (automatyzacja).

DR: Zone 5 jest replikowana do drugiej lokalizacji (cross-region DR). Failover Zone 5: < 30 minut (DNS update + restore).

46.14. Ochrona crown jewels w strefie zarządzania

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 46.1, 46.5, 47.1

Crown jewels — najbardziej wrażliwe zasoby SYLION — rezydują w Zone 5:

Crown Jewel	Ochrona
Root CA key	HSM (FIPS 140-3 Level 3), offline, dual custody
Vault master key	HSM auto-unseal lub Shamir shares (5-of-8)
# Założenia zaufania sprzętowego (Trusted Hardware Assumptions)	
LION opiera się na zaufaniu do następujących	komponentów sprzętowych, nad którymi platforma NIE MA kontroli:
Komponent Producent Zakres zaufania Pixel Titan M2 Google Secure Element Pixel modem (Exynos/Qualcomm) Samsung AMD SEV-SNP AMD Memory encryption Intel TDX Intel Memory encryption HSM (Luna/nShield/CloudHSM) Thales Router GL-INET GL-INET / MediaTek GrapheneOS Community (open-source)	nia Ryzyko rezydualne ment, key storage, attestation Backdoor w firmware Titan = kompromitacja kluczy VPN terminala ung/Qualcomm Baseband processing, radio Backdoor w modemie = przechwycenie ruchu pre-IPsec (przed tunelem) n, attestation CVE-2024-56161, StackWarp, Battering RAM — TEE nie jest absolutną granicą n, attestation CVE-2025-22889, mniej dojrzały niż SEV-SNP /Entrust/AWS Key generation, storage, operations Backdoor w firmware HSM = kompromitacja ALL kluczy. Zero publicznej weryfikowalności firmware Network processing, Wi-Fi/LTE Firmware routera zawiera zamknięte blob-y (modem firmware). Moduły autonomiczne [A] modyfikują tylko software layer OS, kernel, hardening JEDYNY komponent z pełnym audytowalnym kodem źródłowym
Wniosek:** GrapheneOS jest jedynym elementem	stosu, którego kod jest w pełni otwarty i audytowalny. Wszystkie pozostałe komponenty sprzętowe wymagają trust-but-verify: regularna weryfikacja firmware, monitoring anomalii, dywersyfikacja dostawców (AMD + Intel dla TEE, multiple HSM vendors). SYLION NIE twierdzi, że eliminuje ryzyko supply chain sprzętu — minimalizuje ich wpływ przez architekturę defence-in-depth.
Break-glass credentials	Sealed envelope, dual custody, rotacja po użyciu
Terraform state	Encrypted, remote backend, versioned
Backup encryption keys	HSM lub Vault (circular dependency mitigated by HSM)
SIEM data	Encrypted at-rest, integrity-chained, immutable

Ochrona wielowarstwowa: 1. Fizyczna: Zone 5 w dedykowanym segmencie DC z kontrolą dostępu 2. Sieciowa: izolacja Zone 5, brak publicznych endpointów 3. Logiczna: bastion → JIT → dual auth → audit 4. Kryptograficzna: szyfrowanie at-rest i in-transit (mTLS) 5. Proceduralna: change management, separation of duties

Rozdział 47. HSM, PKI, tajemnice i zarządzanie kluczami

47.1. Rola HSM w architekturze

Status: [N] Normatywny Odbiorca: Architekt, PKI Officer Wpływ na baseline: Krytyczny Powiązane rozdziały: 46.14, 47.2, 47.16

HSM (Hardware Security Module) jest fundamentem zaufania kryptograficznego (Root of Trust) w SYLION. HSM przechowuje klucze prywatne najwyższej wrażliwości i wykonuje operacje kryptograficzne na nich bez ujawniania klucza poza HSM.

Funkcje HSM w SYLION: 1. Przechowywanie klucza Root CA (47.2) 2. Operacje podpisu (signing) dla Root CA i Intermediate CA 3. Generowanie kluczy (true random — TRNG) 4. Auto-unseal Vault (46.5) 5. Przechowywanie kluczy szyfrujących backup (46.7)

Wymagania HSM: | Parametr | STANDARD/PRO | STATE | | Certyfikacja | FIPS 140-2 Level 2+ | FIPS 140-3 Level 3 | | Typ | Cloud HSM (AWS CloudHSM, Azure Dedicated HSM) | On-prem (Thales Luna, Utimaco) lub Cloud HSM | | Dostępność | HA (cluster) | HA + DR (cross-region) | | Audit | Pełny log operacji | Pełny log log + tamper-evident |

47.2. Root of Trust

Status: [N] Normatywny Odbiorca: Architekt, PKI Officer Wpływ na baseline: Krytyczny Powiązane rozdziały: 47.1, 47.3, 47.13

Root of Trust to łańcuch zaufania kryptograficznego zaczynający się od klucza Root CA przechowywanego w HSM:

Root CA (offline, HSM) — Intermediate CA (online, HSM lub Vault PKI) — G1 certificate — G2 certificate — Router certificates — Service certificates — Workload certificates

Root CA: - Algorytm: ECDSA P-384 (lub RSA-4096 dla interoperacyjności) - Ważność: 10 lat - Offline: Root CA HSM jest odłączony od sieci. Podłączany wyłącznie do podpisywania Intermediate CA (key ceremony — 47.13) - Backup: zaszyfrowany backup klucza Root CA w oddzielnym HSM (dual location)

Intermediate CA: - Algorytm: ECDSA P-384 - Ważność: 2 lata (rotacja co 18 miesięcy — overlap) - Online: Intermediate CA w HSM online lub Vault PKI engine - Funkcja: wystawia certyfikaty operacyjne (G1, G2, routery, usługi)

47.3. PKI warstwy transportowej

Status: [N] Normatywny Odbiorca: Administrator, PKI Officer Wpływ na baseline: Krytyczny Powiązane rozdziały: 34.1, 33.5, 35.3

PKI transportowa obejmuje certyfikaty używane w tunelach IPsec IKEv2:

Certyfikaty G1: - Wystawiany przez Intermediate CA - CN = FQDN G1, SAN = IP publiczne G1 - Algorytm: ECDSA P-384 - Ważność: 180 dni (STANDARD/PRO), 90 dni (STATE) - Klucz prywatny: HSM (STATE) lub plik PEM (STANDARD/PRO — permissions 0600)

Certyfikaty routerów: - Wystawiany przez Intermediate CA - CN = "router-" - Algorytm: ECDSA P-384 - Ważność: 180 dni (STANDARD/PRO), 90 dni (STATE) - Klucz prywatny: na routerze (pamięć flash, zaszyfrowana)

CRL (Certificate Revocation List): - Wystawiany przez Intermediate CA co 1h (lub on-demand przy unieważnieniu) - Dystrybuowany: G1 pobiera CRL co 1h, cache w pamięci - OCSP (Online Certificate Status Protocol): opcjonalny (jako uzupełnienie CRL)

47.4. PKI usługowa

Status: [N] Normatywny Odbiorca: Architekt, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 34.5, 43.10, 47.3

PKI usługowa obejmuje certyfikaty mTLS dla komunikacji service-to-service:

Wystawianie: Vault PKI engine (secret engine) wystawia certyfikaty: - Automatycznie (cert-manager, SPIFFE/SPIRE) - Na żądanie (API Vault) - Krótkoterminowe: 24–72h (automatyczna rotacja)

Parametry: - Algorytm: ECDSA P-256 (wystarczający dla wewnętrznych certyfikatów) lub P-384 - SAN: service name (DNS), IP - CN: service identifier (np. svc-matrix-homeserver)

Automatyzacja: Cert-manager (Kubernetes) lub SPIRE (SPIFFE runtime environment) automatycznie żąda, rotuje i dystrybuuje certyfikaty do workloadów i usług. Brak manualnej interwencji.

47.5. Certyfikaty G1/G2

Status: [N] Normatywny Odbiorca: PKI Officer, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 35.9, 36.1, 47.3

Certyfikaty G1 i G2 są krytyczne — ich kompromitacja umożliwia podszycie się pod bramę:

G1: - Certyfikat publiczny — przedstawiany routerom przy IKE handshake - Klucz prywatny — przechowywany w HSM (STATE) lub pliku PEM - Rotacja: 180 dni (STANDARD/PRO), 90 dni (STATE) - Unieważnienie: natychmiastowe (CRL + OCSP) w przypadku kompromitacji

G2: - Certyfikat — używany do mTLS z Session Broker i workloadami - Klucz prywatny — przechowywany w Vault lub HSM - Rotacja: 90 dni (wszystkie tery) - Unieważnienie: natychmiastowe

47.6. Certyfikaty usługowe i integracyjne

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 47.4, 43.10, 43.9

Certyfikaty per usługa w Zone 4 i Zone 5: - Matrix homeserver: mTLS cert, krótkoterminowy (72h) - CRM backend: mTLS cert - Forward proxy: mTLS cert + opcjonalnie TLS inspection cert (MITM proxy — kontrowersyjne) - SIEM: mTLS cert (logowanie) - Vault: TLS cert (API)

Automatyczna rotacja przez Vault PKI engine.

47.7. Klucze operatorskie i tenantowe

Status: [N] Normatywny Odbiorca: Architekt, PKI Officer Wpływ na baseline: Wysoki Powiązane rozdziały: 38.7, 44.1, 47.9

Klucze kryptograficzne per operator i per tenant:

Per-tenant encryption key: Klucz szyfrujący dane tenanta (storage encryption layer — nadrzędny): - Przechowywany w Vault lub HSM - Używany do szyfrowania per-operator keys (key hierarchy: tenant key → operator key → workload key)

Per-operator encryption key: Klucz szyfrujący dane operatora (storage volumes — 38.7): - Generowany przy provisioningu operatora - Przechowywany w Vault - Dostarczany do workloadu przy starcie (auto-unseal)

Hierarchia kluczy:

Tenant Key (HSM/Vault) — Operator Key (Vault) — Workload Key (Vault, per workload) — Volume Key (LUKS2, per volume)

47.8. Klucze sesji vs klucze persistent

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 34.3, 37.8, 47.7

Klucze sesji (ephemeral): - Generowane per sesja (IPsec SA, TLS session, DTLS session) - Żywność: od minut do godzin (SA lifetime — 34.3) - PFS: nowy klucz DH przy każdym rekeying — kompromitacja jednego klucza sesji nie ujawnia innych - Nie przechowywane persistent — wyłącznie w pamięci RAM

Klucze persistent: - Klucze prywatne CA, G1, G2, routerów, usług - Żywność: miesiące/lata (z rotacją) - Przechowywane w HSM, Vault lub na dysku (plik PEM z restricted permissions) - Kompromitacja: wymaga natychmiastowego unieważnienia i rotacji

Zasada: Klucze sesji zapewniają confidentiality-forward — nawet kompromitacja klucza persistent (certyfikatu) nie ujawnia historycznego ruchu (dzięki PFS). Dlatego PFS jest obowiązkowy w SYLION (34.2).

47.9. Sealing i auto-unseal

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 46.5, 47.1, 47.7

Sealing (zapieczętowanie) chroni sekrety w Vault na wypadek kompromitacji lub restartu:

Vault seal: Vault przechowuje dane zaszyfrowane „seal key” (master key). Po restarcie Vault jest w stanie „sealed” — nie może odczytać sekretów bez unseal.

Auto-unseal: - Cloud KMS: Vault automatycznie odpieczętowanie się przy starcie używając klucza w cloud KMS (AWS KMS, Azure Key Vault, GCP KMS) - HSM: Vault odpieczętowanie się przy starcie używając klucza w HSM (PKCS#11)

Shamir shares (alternatywa): Seal key jest podzielony na N shares (np. 5), z których K jest wymagane do unseal (np. 3-of-5). Shares dystrybuowane do różnych administratorów. Unseal wymaga obecności K administratorów — zapobiega single-person access.

Rekomendacja SYLION: auto-unseal przez HSM (STATE) lub cloud KMS (STANDARD/PRO). Shamir shares jako backup.

47.10. Rotacja kluczy

Status: [N] Normatywny Odbiorca: Administrator, PKI Officer Wpływ na baseline: Krytyczny Powiązane rozdziały: 33.10, 47.3, 47.5

Rotacja kluczy jest obowiązkowa — żaden klucz nie jest używany permanentnie:

Klucz	Rotacja	Automatyzacja
Root CA	Nie (10 lat, key ceremony do wymiany)	Manual
Intermediate CA	Co 18 miesięcy	Semi-auto (Ansible)
G1 klucz prywatny	180 dni (STD/PRO), 90 dni (STATE)	Ansible + Vault PKI
G2 klucz prywatny	90 dni	Vault PKI auto
Router certyfikat	180 dni (STD/PRO), 90 dni (STATE)	Ansible (through tunnel)
Service certs (mTLS)	24–72h	cert-manager auto
Workload keys	90 dni	Vault auto
Operator storage key	365 dni	Vault auto (re-encrypt)
Database credentials	1–24h (dynamic secrets)	Vault auto

Rotacja jest monitorowana — brak rotacji w wymaganym terminie → alert WARN (14 dni przed expiry), alert HIGH (7 dni), alert CRITICAL (1 dzień).

47.11. Rotacja certyfikatów

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 47.10, 47.3, 47.4

Rotacja certyfikatów obejmuje: generowanie nowego klucza, wystawienie nowego certyfikatu, deployment, unieważnienie starego.

Procedura (automatyczna — cert-manager / Vault PKI): 1. Cert-manager monitoruje expiry certyfikatu 2. 30 dni przed expiry: generowanie nowego klucza, żądanie nowego certyfikatu (CSR → CA) 3. CA wystawia nowy certyfikat (overlap: stary i nowy ważne jednocześnie) 4. Deployment nowego certyfikatu do komponentu 5. Weryfikacja (healthcheck z nowym certyfikatem) 6. Unieważnienie starego certyfikatu (CRL)

Dla certyfikatów krótkoterminowych (24–72h): pełna automatyzacja, brak overlap (nowy certyfikat natychmiast zastępuje stary).

47.12. Rotacja sekretów aplikacyjnych

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 46.5, 47.10, 43.2

Sekrety aplikacyjne (database passwords, API tokens, encryption keys) rotowane przez Vault Dynamic Secrets:

Dynamic secrets: Vault generuje poświadczenie on-demand z TTL (np. 1h). Po wygaśnięciu TTL — Vault automatycznie unieważnia poświadczenie (np. REVOKE w PostgreSQL). Aplikacja żąda nowego poświadczenia.

Korzyść: brak statycznych poświadczeń. Nawet jeśli poświadczenie wycieknie — jest ważne max. TTL (1h).

Encryption key rotation: Dla kluczy szyfrujących dane (storage): rotacja klucza = re-encrypt danych nowym kluczem. Procedura: (a) nowy klucz w Vault, (b) background job: decrypt starym → encrypt nowym, (c) po zakończeniu: unieważnienie starego klucza.

47.13. Key ceremonies

Status: [N] Normatywny Odbiorca: PKI Officer, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 47.2, 47.14, 46.10

Key ceremony to formalna procedura generowania, przechowywania lub rotacji kluczy najwyższej wrażliwości (Root CA, Vault seal key).

Procedura Root CA key ceremony: 1. Planowanie: data, lokalizacja, uczestnicy (min. 3 osoby: ceremoniarz, świadek, notariusz) 2. Środowisko: air-gapped komputer (nigdy podłączony do sieci), HSM, kamera (nagrywanie procedury) 3. Generowanie klucza Root CA na HSM (TRNG) 4. Podpisywanie Intermediate CA certyfikatu kluczem Root CA 5. Backup klucza Root CA (jeśli HSM wspiera backup — zaszyfrowany, dual location) 6. Zapieczętowanie HSM z kluczem Root CA (offline) 7. Dokumentacja: protokół ceremonii podpisany przez wszystkich uczestników 8. Nagranie video archiwizowane

Częstotliwość: Root CA key ceremony: co 10 lat (lub wcześniej w przypadku kompromitacji). Intermediate CA: co 2 lata.

47.14. Split knowledge i dual control

Status: [N] Normatywny Odbiorca: PKI Officer, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 46.10, 47.13, 44.15

Split knowledge: Żadna pojedyncza osoba nie zna całego sekretu. Przykład: Vault seal key podzielony na 5 shares (Shamir) — żadna osoba nie posiada więcej niż 1 share.

Dual control: Operacja na sekrecie wymaga obecności co najmniej dwóch osób. Przykład: key ceremony wymaga ceremoniarz + świadek; break-glass wymaga dwóch administratorów.

Implementacja w SYLION: - Vault unseal: 3-of-5 Shamir shares (lub auto-unseal HSM — split knowledge na poziomie HSM access) - Root CA key ceremony: min. 3 osoby - Break-glass: dual auth (46.10) - Emergency re-enrollment: dual auth (44.15)

47.15. Integracja HSM z warstwą operacyjną

Status: [N] Normatywny Odbiorca: Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 47.1, 35.9, 46.5

HSM integruje się z komponentami SYLION przez standardowe interfejsy:

PKCS#11: - strongSwan (G1): PKCS#11 plugin do podpisywania IKE_AUTH kluczem przechowywanym w HSM - Vault: PKCS#11 seal plugin (auto-unseal)

KMIP (Key Management Interoperability Protocol): - Vault Enterprise: KMIP seal - Interop z enterprise HSM (Thales, Utimaco, nCipher)

Cloud KMS API: - AWS CloudHSM: AWS SDK - Azure Dedicated HSM: Azure SDK - GCP Cloud HSM: GCP SDK

Latencja HSM: < 10 ms per operacja (signing, decrypt). Przepustowość: > 1000 operacji/sekundę (wystarczające dla IKE handshake na G1).

47.16. HSM on-prem vs cloud HSM

Status: [R] Rekomendowany Odbiorca: Architekt, Decydent Wpływ na baseline: Wysoki Powiązane rozdziały: 47.1, 47.15, 51.3

Kryterium	On-prem HSM	Cloud HSM
Kontrola fizyczna	Pełna (organizacja)	Partial (cloud provider)
Certyfikacja	FIPS 140-3 Level 3	FIPS 140-2/3 Level 2-3
Koszt	Wysoki (10k-50k EUR + utrzymanie)	Niski (1-2 EUR/h)
HA	Cluster (manual setup)	Automatyczny (multi-AZ)
Latencja	< 1 ms (local)	< 5 ms (network)
Jurysdykcja	Kontrolowana (organizacja)	Cloud provider jurisdiction
Audit	Pełny (local logs)	Cloud provider logs

Rekomendacja: - STANDARD/PRO: Cloud HSM (koszt-efektywny, HA automatyczny) - STATE: On-prem HSM (pełna kontrola, jurysdykcja, FIPS Level 3)

47.17. Klasyfikacja i lifecycle sekretów

Status: [N] Normatywny Odbiorca: Administrator, PKI Officer Wpływ na baseline: Wysoki Powiązane rozdziały: 47.1, 47.10, 46.5

Każdy sekret w SYLION jest klasyfikowany:

Klasyfikacja	Przykłady	Przechowywanie	Dostęp
CRITICAL	Root CA key, Vault seal key	HSM offline	Key ceremony, dual control
HIGH	G1/G2 klucze, operator keys	HSM/Vault	Admin-pki, dual auth (STATE)
MEDIUM	Service certs, API tokens	Vault	Admin-infra, automated
LOW	Ephemeral session keys	RAM only	Automated, no persistence

Lifecycle sekretu: Generation → Storage → Distribution → Usage → Rotation → Revocation → Destruction

Każda faza jest logowana. Destruction: kryptograficzne wymazanie (zero-write, key deletion in HSM). Potwierdzenie destrukcji: logowane w audyt trail.

Rozdział 48. Moduł AI/ML i ModelOps

48.1. Zakres AI w SYLION

Status: [R] Rekomendowany Odbiorca: Architekt, Decydent Wpływ na baseline: Średni Powiązane rozdziały: 43.4, 48.2, 48.13

Sztuczna inteligencja w SYLION pełni rolę wspomagającą — nie decyzyjną. AI nie podejmuje autonomicznych decyzji bezpieczeństwa (np. zablokowanie operatora) — dostarcza rekomendacje, które są weryfikowane przez ludzi lub egzekwowane przez polityki zdefiniowane przez ludzi.

Zakres zastosowań AI: 1. Analityka i automatyzacja (48.2): klasyfikacja wiadomości, streszczanie, tłumaczenie, generowanie raportów 2. Operacje i detekcja anomalii (48.3): UEBA (User and Entity Behavior Analytics), detekcja anomalii sieciowych, detekcja lateral movement 3. Rekomendacje polityk (48.4): sugerowanie zaostrożenia polityk na podstawie wzorców ryzyka 4. Triage incydentów (48.5): automatyczna klasyfikacja i priorytetyzacja alertów SIEM 5. Workflows LLM (48.6): asystent operatora (chatbot w env-matrix), analiza dokumentów

Zasada: AI jest narzędziem operatora i administratora — nie autonomicznym agentem. Każda akcja sugerowana przez AI wymaga potwierdzenia człowieka (human-in-the-loop) dla operacji o impact ≥ MEDIUM. Dla operacji o niskim impact (np. klasyfikacja alertu) — automatyzacja dozwolona z audytem.

48.2. AI dla analityki i automatyzacji

Status: [R] Rekomendowany Odbiorca: Administrator, Operator Wpływ na baseline: Niski Powiązane rozdziały: 48.1, 43.4, 48.6

AI w Zone 4 udostępnia operatorom narzędzia analityczne:

Zastosowania: - Tłumaczenie: Real-time translation w env-matrix (model: M2M-100 lub NLLB self-hosted) - Streszczanie: Automatyczne streszczenia długich wątków Matrix - Generowanie tekstu: Drafty emaili, notatek, raportów - Klasyfikacja dokumentów: Automatyczne tagowanie plików (typ, temat, wrażliwość) - OCR: Rozpoznawanie tekstu z obrazów/skanów (Tesseract + model ML)

Deployment: Modele działają w Zone 4 jako usługi (API): - Modele open-source: Llama 3, Mistral, Phi — self-hosted na GPU server w Zone 4 - Inference API: REST/gRPC, uwierzytelnienie mTLS + OIDC - Brak wysyłania danych do zewnętrznych API LLM (OpenAI, Claude, Gemini) — chyba że z anonimizacją (PII stripping)

48.3. AI dla operacji i detekcji anomalii

Status: [R] Rekomendowany Odbiorca: SOC, Administrator Wpływ na baseline: Średni Powiązane rozdziały: 48.1, 46.6, 50.1

AI wspomaga operacje bezpieczeństwa:

UEBA (User and Entity Behavior Analytics): Model ML (unsupervised — autoencoder, isolation forest) uczy się normalnych wzorców zachowania operatorów: godziny logowania, workloady używane, wolumen eksportu, wzorce network traffic. Anomalia (odchylenie od baseline) → alert z confidence score.

Detekcja anomalii sieciowych: Model analizuje NetFlow/IPFIX z G1 (35.6): nietypowe wolumeny ruchu, nowe destination IP, anomalne wzorce portów. Korelacja z threat intelligence feeds.

Detekcja lateral movement: Model monitoruje komunikację workload → workload (38.10) i workload → Zone 4. Nietypowa komunikacja (nowy endpoint, nowy port, zmieniony wolumen) → alert.

Implementacja: - Modele trenowane na danych historycznych (baseline: 30 dni) - Retraining: co 7 dni (automatyczny pipeline — 48.13) - False positive management: SOC raportuje false positives → feedback loop → model improvement - Alerty AI trafiają do SIEM z oznaczeniem source: ML i confidence: 0.0–1.0

48.4. AI dla rekomendacji polityk

Status: [O] Opcjonalny Odbiorca: Administrator Wpływ na baseline: Niski Powiązane rozdziały: 48.1, 45.1, 45.12

AI analizuje dane historyczne (decyzje G2, incydenty, anomalie) i sugeruje zmiany polityk:

Przykłady rekomendacji: - „Operator X regularnie eksportuje pliki poza godzinami pracy — rozważ ograniczenie czasowe” - „Workload env-browser ma 30% wzrost egress — rozważ zaostrzenie URL filtering” - „Certyfikat routera Y wygasał 3 razy bez rotacji — rozważ automatyzację”

Workflow: 1. AI generuje rekomendację (background job, co 24h) 2. Rekomendacja trafia do administratora (Matrix #policy-recommendations) 3. Administrator ocenia: accept / reject / defer 4. Accept → change request (46.8) → standard process 5. Feedback loop: accept/reject → model improvement

Human-in-the-loop: Rekomendacja AI NIGDY nie jest automatycznie wdrażana — zawsze wymaga decyzji administratora.

48.5. AI dla triage incydentów

Status: [R] Rekomendowany Odbiorca: SOC Wpływ na baseline: Średni Powiązane rozdziały: 48.1, 50.1, 50.6

AI wspomaga triage (wstępna ocena i priorytetyzacja) alertów z SIEM:

Automatyczny triage: 1. Alert z SIEM → AI model (classifier) 2. Model klasyfikuje: severity (CRITICAL/HIGH/MEDIUM/LOW), category (access violation, anomaly, malware, policy), confidence 3. Alert z klasyfikacją trafia do SOC dashboard 4. SOC weryfikuje klasyfikację i podejmuje decyzję

Korzyść: Redukcja alert fatigue — typowy SIEM generuje setki/tysiące alertów dziennie. AI filtruje i priorytetyzuje, pozwalając SOC skupić się na krytycznych.

Model: Supervised classifier (Random Forest, XGBoost, lub fine-tuned LLM) trenowany na historycznych alertach z etykietami SOC (true positive / false positive / category).

Ograniczenia: - AI może przeoczyć nowy typ ataku (zero-day — brak w danych treningowych) - False negatives (AI ocenia alert jako LOW, ale jest CRITICAL) → SOC review losowej próbki alertów LOW (sampling) - AI nie zastępuje SOC — wspomagający

48.6. Workflowy LLM

Status: [O] Opcjonalny Odbiorca: Operator, Administrator Wpływ na baseline: Niski Powiązane rozdziały: 48.1, 48.2, 43.4

LLM (Large Language Model) może być udostępniony operatorom jako asystent:

Scenariusze: - Chatbot w env-matrix: operator zadaje pytania → LLM odpowiada (knowledge base, dokumentacja, FAQ) - Analiza dokumentów: LLM streszcza, wyciąga kluczowe informacje z dokumentów w env-office - Drafty: LLM generuje drafty emaili, notatek, raportów

Deployment: - Model self-hosted (Zone 4): Llama 3 70B, Mistral Large, lub mniejsze modele (Phi-3, Gemma) - GPU server: NVIDIA A100/H100 lub AMD MI300 (konfiguracja zależna od rozmiaru modelu) - API: OpenAI-compatible API (vLLM, llama.cpp, Ollama) - Integracja: Element bot w Matrix, lub dedykowany interfejs w env-office

Bezpieczeństwo LLM: - Dane przesyłane do LLM nie opuszczają Zone 4 (self-hosted) - Prompt injection: walidacja inputu (48.11) - Output sanitization: output LLM nie jest automatycznie wykonywany - Logging: prompt + response logowane (dla audytu, nie dla treningu modelu)

48.7. Rejestr modeli

Status: [R] Rekomendowany Odbiorca: DevOps, Administrator Wpływ na baseline: Niski Powiązane rozdziały: 48.6, 48.8, 48.9

Model registry przechowuje informacje o modelach ML wdrożonych w SYLION:

Pole	Opis
model_id	Unikalny identyfikator modelu
model_name	Nazwa (np. anomaly-detector-v3)
model_version	Semver
model_type	Classification / Regression / LLM / Embedding
model_hash	SHA-256 artefaktu modelu
training_date	Data treningu
training_data_hash	Hash danych treningowych
performance_metrics	Accuracy, Precision, Recall, F1, AUC
deployment_status	staging / production / retired
owner	Team / person

Registry: MLflow (open source) lub custom (database in Zone 4).

48.8. Deployment modeli

Status: [R] Rekomendowany Odbiorca: DevOps Wpływ na baseline: Niski Powiązane rozdziały: 48.7, 48.9, 43.4

Modele ML są deployowane jako usługi w Zone 4:

Pipeline: 1. Training: model trenowany w dedykowanym środowisku (GPU server, Zone 4) 2. Validation: testy na zbiorze testowym, porównanie z baseline 3. Packaging: model zapakowany jako kontener (OCI image) z inference server (TorchServe, Triton, vLLM) 4. Signing: artefakt podpisany (Ed25519) 5. Registry:

rejestracja w model registry (48.7) 6. Deployment: blue-green deployment na inference server (Zone 4) 7. Monitoring: metryki inference (latency, throughput, error rate — 48.9)

Rollback: Jeśli nowy model pogarsza metryki → automatyczny rollback do poprzedniej wersji.

48.9. Monitoring modeli

Status: [R] Rekomendowany Odbiorca: DevOps, SOC Wpływ na baseline: Niski Powiązane rozdziały: 48.7, 48.8, 48.10

Monitoring modeli ML obejmuje:

Metryki operacyjne: - Inference latency (p50, p95, p99) - Throughput (requests/second) - Error rate - GPU utilization, memory utilization

Metryki jakości (drift detection): - Data drift: rozkład danych wejściowych zmienia się w czasie → model może tracić jakość - Concept drift: relacja input → output zmienia się → model wymaga retrainingu - Performance drift: accuracy/F1 na production data spada poniżej threshold → alert

Alerting: - Inference latency > 500 ms → alert MEDIUM - Error rate > 5% → alert HIGH - Data drift detected → alert INFO (wymaga review) - Performance drift → alert WARN (wymaga retraining)

48.10. Governance modeli

Status: [R] Rekomendowany Odbiorca: Decydent, Administrator Wpływ na baseline: Średni Powiązane rozdziały: 48.7, 48.9, 48.11

Governance modeli AI zapewnia odpowiedzialność, transparentność i kontrolę:

Wymagania: - Każdy model ma właściciela (person/team) odpowiedzialnego za utrzymanie - Każdy model ma dokumentację: cel, dane treningowe, metryki, ograniczenia, biasy - Przed deploymentem: review (team bezpieczeństwa + owner) - Modele używające danych osobowych: ocena wpływu na prywatność (DPIA per RODO) - Modele podejmujące decyzje wpływające na operatorów: wymóg explain ability (dlaczego model podjął taką decyzję)

Retirement: Modele nieużywane > 90 dni → review. Modele z performance drift nienaprawione > 30 dni → retirement.

48.11. Bezpieczeństwo modeli (adversarial inputs, prompt injection)

Status: [N] Normatywny Odbiorca: Architekt, SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 48.1, 48.6, 43.4

Modele AI są podatne na specyficzne wektory ataku:

Adversarial inputs: Specjalnie spreparowane dane wejściowe mogą oszukać model (np. obraz z imperceptible perturbation klasyfikowany błędnie). Mitigacja: adversarial training, input validation, ensemble models.

Prompt injection (LLM): Operator lub napastnik wstrzykuje instrukcje do promptu LLM, powodując ujawnienie danych systemowych, instrukcji, lub wykonanie niezamierzonej akcji. Mitigacja: - System prompt isolation (LLM nie ujawnia system promptu) - Input sanitization (usuwanie potencjalnie złośliwych instrukcji) - Output filtering (blokada ujawnienia sekretów, PII) - Sandboxing: LLM nie ma dostępu do systemów zewnętrznych (brak tool-use w baseline) - Monitoring: analiza logów prompt/response pod kątem anomalii

Model poisoning: Jeśli model jest trenowany na danych z niekontrolowanego źródła — napastnik może zatruć dane treningowe. Mitigacja: walidacja źródła danych, hash weryfikacja, curated datasets.

Supply chain: Modele pobierane z zewnątrz (HuggingFace, model zoos) mogą zawierać backdoor. Mitigacja: weryfikacja hash, skanowanie (model scanning tools), preferowanie modeli z zaufanych źródeł.

48.12. Governance danych dla AI

Status: [R] Rekomendowany Odbiorca: DPO, Administrator Wpływ na baseline: Średni Powiązane rozdziały: 48.1, 48.10, 39.5

Dane używane do treningu i inference modeli AI podlegają governance:

Zasady: - Dane operatorów (wiadomości, dokumenty) NIE są używane do treningu modeli bez jawnej zgody - Dane treningowe są anonimizowane (PII stripping) przed trenowaniem - Dane treningowe mają retention policy (usuwane po trenowaniu, chyba że wymagane do reprodukcji) - Dane inference (prompt + response) logowane do audytu, ale nie do trenowania (chyba że jawna zgoda) - RODO: operator ma prawo do informacji, czy jego dane były użyte do treningu, i do usunięcia

48.13. Pipeline ModelOps

Status: [R] Rekomendowany Odbiorca: DevOps Wpływ na baseline: Niski Powiązane rozdziały: 48.7, 48.8, 48.9

Pipeline ModelOps automatyzuje cykl życia modelu:

[Data ingestion] → [Feature engineering] → [Training] → [Validation] → [Registry] ↓ [Deployment] ↓ [Monitoring] ↓ [Retraining trigger] ↓ [Training] (loop)

Narzędzia: MLflow (registry + tracking), Kubeflow / Airflow (pipeline orchestration), Prometheus (monitoring). Wszystko self-hosted w Zone 4/5.

48.14. Ryzyka i ograniczenia AI

Status: [N] Normatywny Odbiorca: Decydent, Architekt Wpływ na baseline: Średni Powiązane rozdziały: 48.1, 48.11, 48.10

Ryzyka: 1. Halucynacje LLM: Model generuje fałszywe informacje z dużą pewnością. Mitygacja: human-in-the-loop, citation requirement 2. Bias: Model reprodukuje biasy z danych treningowych. Mitygacja: audyt fairness, diverse datasets 3. Overreliance: Operatorzy polegają na AI zamiast własnej oceny. Mitygacja: szkolenie, oznaczanie rekomendacji AI jako „sugestia” 4. Privacy leakage: Model ujawnia dane treningowe (membership inference, data extraction). Mitygacja: differential privacy, ograniczony dostęp do modelu 5. Compute cost: LLM wymaga GPU — wysoki koszt operacyjny. Mitygacja: mniejsze modele, quantization, batching

Ograniczenia: - AI nie zastępuje SOC, administratora ani operatora — wspomagający - AI nie podejmuje decyzji bezpieczeństwa autonomicznie (human-in-the-loop) - AI nie jest w baseline STANDARD — opcjonalny w PRO, rekomendowany w STATE

Rozdział 49. OTA i dystrybucja oprogramowania

49.1. Zakres OTA w SYLION

Status: [N] Normatywny Odbiorca: Administrator, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 32.4, 33.4, 49.2

OTA (Over-The-Air) w kontekście SYLION obejmuje dystrybucję aktualizacji oprogramowania i konfiguracji do wszystkich komponentów systemu — terminali, routerów i infrastruktury.

Komponenty aktualizowane OTA: 1. Klient terminala SYLION (Android app, desktop app — 49.2) 2. Firmware routera (OpenWrt hardened — 49.3) 3. Komponenty infrastruktury (G1, G2, Session Broker, Zone 4 services — 49.4) 4. Polityki OPA/Rego (45.3 — dystrybucja bundle) 5. Bazy sygnatur (AV, YARA, threat intel — 42.4) 6. Modele AI (48.8)

Zasada: Każda aktualizacja musi być podpisana, zweryfikowana i wdrożona w kontrolowany sposób. Brak mechanizmu bypass — nawet emergency update przechodzi pipeline podpisu.

49.2. Aktualizacja klienta terminala

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 32.2, 32.4, 49.5

Android (Pixel): Klient SYLION (VPN + sesja) dystrybuowany przez: - Managed Google Play (profil roboczy MDM) — preferowany. MDM wymusza automatyczną instalację - Sideload (APK) — dla scenariuszy bez Google Play. APK podpisany kluczem SYLION

Desktop: Klient desktopowy dystrybuowany przez: - Pakiet systemowy (DEB/RPM na Linuksie, DMG na macOS, MSI na Windows) — przez MDM lub repo - Flatpak/Snap (Linux) — z dedykowanego repozytorium SYLION

Wymuszenie aktualizacji: MDM może wymusić aktualizację klienta w ciągu: 72h (STANDARD), 48h (PRO), 24h (STATE). Brak aktualizacji → terminal non-compliant → G2 DENY.

49.3. Aktualizacja routera

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 33.4, 33.14, 49.5

Firmware routera aktualizowany przez tunel IPsec zarządzania:

Procedura: 1. Nowy firmware zbudowany w CI/CD (reproducible build — 49.6) 2. Firmware podpisany (Ed25519) 3. Firmware umieszczony w repozytorium artefaktów (Zone 5) 4. Ansible playbook: (a) download firmware na router (SCP przez tunel), (b) weryfikacja podpisu, (c) sysupgrade z weryfikacją, (d) router reboot, (e) healthcheck (tunel re-established, config hash match) 5. Rollback: jeśli router nie ustanawia tunelu w ciągu 5 minut po upgrade → automatyczny rollback na poprzedni firmware (OpenWrt sysupgrade -b preservuje backup)

Rolling update: Routery aktualizowane sekwencyjnie (nie jednocześnie) — max. 10% floty na raz. Monitoring po każdej grupie. Awaria > 2 routerów → wstrzymanie rollout.

49.4. Aktualizacja komponentów infrastruktury

Status: [N] Normatywny Odbiorca: Administrator, DevOps Wpływ na baseline: Wysoki Powiązane rozdziały: 35.11, 46.3, 49.5

Komponenty infrastruktury (G1, G2, Session Broker, Zone 4 services) aktualizowane przez immutable infrastructure model:

Procedura: 1. Nowy obraz komponentu zbudowany w CI/CD 2. Obraz podpisany (cosign / Ed25519) 3. Obraz zarejestrowany w artifact registry (43.5) 4. Blue-green deployment (35.11): nowa instancja obok starej 5. Healthcheck → traffic shift 6. Stara instancja: utrzymywana 24h (rollback), następnie usuwana

Dla Zone 4 services (Kubernetes): Rolling update z readiness/liveness probes. Max unavailable: 25%. Rollback: kubectl rollout undo.

49.5. Podpisywanie artefaktów

Status: [N] Normatywny Odbiorca: DevOps, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 49.1, 49.6, 43.5

Każdy artefakt dystrybuowany w SYLION musi być podpisany:

Klucz podpisu: - Ed25519 (preferowany) lub ECDSA P-384 - Klucz prywatny przechowywany w HSM lub Vault (46.5) - Klucz publiczny dystrybuowany do komponentów (wbudowany w klienta, firmware, konfigurację)

Narzędzia: - Sigstore / cosign: Dla kontenerów OCI - OpenBSD signify / minisign: Dla plików (firmware, pakiety) - GPG: Opcjonalny (kompatybilność z ekosystemem DEB/RPM)

Weryfikacja: Każdy komponent weryfikuje podpis przed instalacją/ladowaniem: - Router: sysupgrade z weryfikacją podpisu - Klient Android: Android APK signing (plus weryfikacja certyfikatu SYLION) - OPA: bundle signature verification - Kontener: cosign verify

Brak ważnego podpisu = odmowa instalacji. Brak wyjątków.

49.6. Reproducible builds

Status: [R] Rekomendowany Odbiorca: DevOps, Architekt Wpływ na baseline: Średni Powiązane rozdziały: 49.5, 33.4, 43.5

Reproducible builds zapewniają, że artefakt może być odtworzony z tych samych źródeł — weryfikacja, że build pipeline nie został skompromitowany.

Wymagania: - Pinowane wersje wszystkich zależności (lockfile) - Deterministic build environment (kontener Docker z pinowanym image) - Timestamp normalizacja (SOURCE_DATE_EPOCH) - Brak non-deterministic elementów (random, timestamp-based filenames) - Hash artefaktu: SHA-256, publikowany w manifest

Weryfikacja: Niezależna strona (audytor, drugi build server) może zbudować artefakt z tych samych źródeł i porównać hash. Identyczny hash = build nie był manipulowany.

Reproducible builds są rekomendowane dla firmware routera (33.4) i klienta terminala (49.2). Dla kontenerów infrastruktury: best-effort (pełna reprodukowalność kontenerów jest trudniejsza).

49.7. Walidacja po stronie klienta

Status: [N] Normatywny Odbiorca: Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 49.5, 49.2, 49.3

Klient (terminal, router) weryfikuje każdą aktualizację przed instalacją:

Kroki walidacji: 1. Podpis: weryfikacja Ed25519/ECDSA podpisu artefaktu kluczem publicznym SYLION 2. Hash: porównanie SHA-256 pobranego artefaktu z hash w manifest (podpisany) 3. Wersja: weryfikacja, że nowa wersja > aktualna (zapobieganie downgrade attack) 4. Kompatybilność: weryfikacja, że artefakt jest przeznaczony dla tego modelu/platformy 5. Integralność: po instalacji — weryfikacja, że zainstalowany artefakt == pobrany (hash post-install)

Failure na dowolnym kroku → odmowa instalacji + alert.

49.8. Strategie rollout

Status: [N] Normatywny Odbiorca: Administrator, DevOps Wpływ na baseline: Średni Powiązane rozdziały: 49.1, 49.3, 49.9

Aktualizacje są wdrażane stopniowo (nie jednocześnie):

Canary deployment: 1. Aktualizacja 1% floty (canary group — wewnętrzni testers) 2. Monitoring przez 24h: metryki, alerty, user feedback 3. Jeśli OK → rozszerzenie na 10% 4. Monitoring 24h → rozszerzenie na 50% 5. Monitoring 24h → rozszerzenie na 100%

Rollout schedule: | Faza | % floty | Czas monitoringu | Rollback trigger | |—|—|—|—| | Canary | 1% | 24h | Jakiegokolwiek issue | | Early adopters | 10% | 24h | > 1% failure rate | | Majority | 50% | 24h | > 0.5% failure rate | | Full | 100% | 48h monitoring | > 0.1% failure rate |

Emergency update: W przypadku krytycznej luki bezpieczeństwa (CVE CRITICAL) — skrócony rollout: canary (1h) → 100% (24h). Akceptowane wyższe ryzyko regresji kosztem szybkości.

49.9. Strategie rollback

Status: [N] Normatywny Odbiorca: Administrator, DevOps Wpływ na baseline: Wysoki Powiązane rozdziały: 49.8, 49.3, 49.4

Każda aktualizacja musi mieć zdefiniowany plan rollback:

Router: OpenWrt sysupgrade zachowuje backup konfiguracji. Rollback: reflash poprzedniego firmware (przechowywany na partycji failsafe) lub remote reflash przez Ansible.

Infrastruktura: Blue-green: rollback = przełączenie ruchu na starą instancję (< 5 minut). Kubernetes: kubectl rollout undo deployment/<name>.

Klient terminala: MDM: rollback do poprzedniej wersji APK/pakietu. Android: APK downgrade (wymaga --allow-downgrade w ADB lub MDM force install).

Kluczowa zasada: Rollback musi być szybszy niż deployment (< 15 minut). Rollback plan jest testowany w staging przed każdym rollout.

49.10. Bezpieczeństwo pipeline aktualizacji

Status: [N] Normatywny Odbiorca: Architekt, DevOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 49.5, 49.6, 46.14

Pipeline aktualizacji (CI/CD) jest krytycznym elementem łańcucha zaufania — kompromitacja pipeline = dystrybucja złośliwego oprogramowania do całej floty.

Ochrona: 1. Access control: Dostęp do pipeline (GitLab CI runners, build servers) ograniczony do admin-infra (JIT) 2. Immutable runners: Build runners są ephemeral (odtworzane od zera per build) 3. Signing: Artefakty podpisywane kluczem w HSM (klucz nie opuszcza HSM) 4. Code review: Każda zmiana kodu wymaga review (min. 1 reviewer) przed merge 5. Branch protection: Main branch protected — brak direct push, wymagany PR + review 6. SBOM (Software Bill of Materials): Generowany przy każdym build — lista zależności z wersjami i licencjami 7. Vulnerability scanning: Skanowanie zależności (Trivy, Gripe) przy każdym build 8. Audit trail: Pełny log: kto commitował, kto reviewował, kto zatwierdził, hash artefaktu

49.11. OTA w środowiskach restrykcyjnych

Status: [O] Opcjonalny Odbiorca: Administrator (STATE) Wpływ na baseline: Niski Powiązane rozdziały: 49.1, 34.12, 51.6

W środowiskach restrykcyjnych (air-gapped, low-bandwidth, hostile network) OTA wymaga adaptacji:

Air-gapped: - Aktualizacje dostarczane na fizycznym nośniku (USB drive, encrypted) - Nośnik: zaszyfrowany (LUKS), podpisany manifest - Procedura: (a) download artefaktów na secure workstation, (b) transfer na nośnik, (c) fizyczny transport do lokalizacji, (d) instalacja z nośnika (weryfikacja podpisu)

Low-bandwidth (Starlink, LTE ograniczony): - Delta updates: zamiast pełnego obrazu — delta (bsdiff/xdelta3). Rozmiar: 10–30% pełnego obrazu - Compression: zstd lub xz - Resume: przerwany download jest wznowiany (HTTP range requests)

Hostile network: - OTA przez tunel IPsec (standard) — artefakty pobierane z repozytorium w Zone 5 przez tunel - Integrity: podpis + hash weryfikowane na kliencie (nawet jeśli sieć jest hostile)

Rozdział 50. Zarządzanie incydentami i playbooki IR

50.1. Moduł zarządzania incydentami

Status: [N] Normatywny Odbiorca: SOC, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 46.6, 50.2, 50.4

Moduł zarządzania incydentami jest systemem koordynującym reakcję na zdarzenia bezpieczeństwa w SYLION. Obejmuje: detekcję, triage, konteneryzację, eradykację, odtworzenie i zamknięcie incydentu.

Definicja incydentu: Zdarzenie bezpieczeństwa, które: (a) narusza poufność, integralność lub dostępność danych/systemów SYLION, lub (b) stanowi naruszenie polityki bezpieczeństwa, lub (c) jest próbą takiego naruszenia.

Klasyfikacja severity: | Severity | Opis | SLA reaction | SLA resolution | |—|—|—| | CRITICAL | Kompromitacja infrastruktury, wyciek danych | 15 minut | 4 godziny | | HIGH | Kompromitacja workloadu, próba exfiltracji | 30 minut | 8 godzin | | MEDIUM | Anomalia, policy violation | 2 godziny | 24 godziny | | LOW | Alert informacyjny, minor policy deviation | 8 godzin | 72 godziny |

50.2. Integracja SIEM/SOAR

Status: [N] Normatywny Odbiorca: SOC, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 46.6, 50.1, 50.3

SIEM (Security Information and Event Management) dostarcza detekcję. SOAR (Security Orchestration, Automation and Response) automatyzuje odpowiedź.

SIEM (patrz 46.6): Wazuh, ELK (Elastic Stack), lub Splunk. Agregacja logów, korelacja, reguły detekcji.

SOAR: - Shuffle (open source) lub Palo Alto XSOAR / Splunk SOAR - Automatyzacja: po wykryciu alertu → automatyczne uruchomienie playbooku - Orchestration: koordynacja między komponentami (G2 — blokada operatora, MDM — remote wipe, Vault — unieważnienie kluczy)

Integracja: SIEM alert → SOAR trigger → playbook execution → notification (Matrix #incidents) → SOC review.

50.3. Automatyzacja odpowiedzi

Status: [R] Rekomendowany Odbiorca: SOC Wpływ na baseline: Średni Powiązane rozdziały: 50.2, 50.4, 48.5

Automatyzacja IR (Incident Response) dla scenariuszy o jednoznacznej reakcji:

Trigger	Automatyczna akcja	Human review
Device non-compliant (heartbeat)	Session terminated by G2	Nie (standard flow)
Malware detected (CDR)	File quarantined	Tak (SOC review)
Failed auth > 10 w 5 min	Account locked 30 min	Tak (SOC notification)
Risk score > 90	All sessions terminated	Tak (SOC review)
Config drift on G1/G2	Alert CRITICAL, snapshot	Tak (SOC immediate)
Operator duress signal	Silent alert to SOC	Tak (SOC immediate)

Automatyzacja dotyczy wyłącznie defensywnych akcji (blokada, terminowanie sesji, kwarantanna). Akcje ofensywne (investigating, reaching out) — wyłącznie SOC.

50.4. Workflow incydentu (detect → triage → contain → eradicate → recover → close)

Status: [N] Normatywny Odbiorca: SOC, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 50.1, 50.3, 50.5

1. Detect (Detekcja): Źródła: SIEM alert, AI anomaly detection (48.3), raport operatora, zewnętrzne powiadomienie (CERT, vendor advisory).
2. Triage (Wstępna ocena — 50.6): SOC ocenia: czy to prawdziwy incydent? Jaki severity? Jaki scope? Kto jest dotknięty?
3. Contain (Konteneryzacja): Powstrzymanie rozprzestrzeniania: izolacja skompromitowanego workloadu (38.11), blokada operatora (G2 DENY), unieważnienie certyfikatów, blokada egress.
4. Eradicate (Eradykacja): Usunięcie przyczyny: rebuild workloadu (38.11/38.12), rotacja kluczy (47.10), aktualizacja polityk (45.1), patching (49.1).
5. Recover (Odtworzenie): Przywrócenie normalnej operacji: odblokowanie operatora, przywrócenie workloadu z czystego image, restore danych z backupu (jeśli potrzebne).
6. Close (Zamknięcie — 50.10): Dokumentacja, lessons learned, aktualizacja playbooków, communication.

50.5. Eskalacje

Status: [N] Normatywny Odbiorca: SOC, Management Wpływ na baseline: Wysoki Powiązane rozdziały: 50.1, 50.4, 46.9

Eskalacja incydentu do wyższego poziomu zarządzania:

Severity	Eskalacja L1	Eskalacja L2	Eskalacja L3
CRITICAL	Natychmiast: SOC lead	15 min: CISO	30 min: Management
HIGH	30 min: SOC lead	2h: admin-security	4h: CISO
MEDIUM	2h: SOC lead	8h: admin-security	N/A
LOW	8h: review	N/A	N/A

Eskalacja obejmuje: status incydentu, scope, impact assessment, recommended actions. Kanał eskalacji: Matrix (#incidents-escalation), telefon (CRITICAL).

50.6. Triage

Status: [N] Normatywny Odbiorca: SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 50.4, 48.5, 50.7

Triage to wstępna ocena alertu/zdarzenia:

Checklist triage: 1. Czy alert jest true positive? (weryfikacja z logami, kontekstem) 2. Jaki jest scope? (jeden operator, wiele operatorów, infrastruktura) 3. Jaki jest impact? (confidentiality, integrity, availability) 4. Jaki severity? (CRITICAL/HIGH/MEDIUM/LOW) 5. Czy wymaga natychmiastowej konteneryzacji? 6. Kto jest odpowiedzialny (assign)?

AI-assisted triage (48.5): AI wstępnie klasyfikuje alert — SOC weryfikuje.

Czas triage: CRITICAL: < 5 minut, HIGH: < 15 minut, MEDIUM: < 30 minut, LOW: < 2 godziny.

50.7. Timeline incydentu

Status: [N] Normatywny Odbiorca: SOC, Audytor Wpływ na baseline: Wysoki Powiązane rozdziały: 50.4, 50.8, 50.10

Każdy incydent musi mieć udokumentowaną timeline:

Czas	Zdarzenie	Źródło
T+0	Alert wygenerowany	SIEM
T+5min	Triage: severity = HIGH	SOC analyst
T+10min	Contain: workload isolated	SOAR
T+30min	Eradicate: workload rebuilt	Ansible
T+1h	Recover: operator restored	G2
T+2h	Close: documentation complete	SOC lead

Timeline jest generowany automatycznie z logów SIEM/SOAR i uzupełniany manualnie przez SOC. Timeline jest częścią raportu post-incident (50.10).

50.8. Zbieranie artefaktów

Status: [N] Normatywny Odbiorca: SOC, Forensic Wpływ na baseline: Wysoki Powiązane rozdziały: 50.4, 50.7, 46.6

Artefakty forensic zbierane podczas incydentu:

Typy artefaktów: - Logi: SIEM logs (filtrowane per incydent), G2 decisions, firewall logs, IKE logs - Snapshoty: Snapshot skompromitowanego workloadu (filesystem + memory dump) - Network capture: PCAP (jeśli dostępny — limitowany, privacy concerns) - Config: Konfiguracja komponentów w momencie incydentu (config hash, policy version) - Timeline: Automatycznie generowana timeline - Indicators of Compromise (IoC): IP adresy, hash plików, domeny, user-agents

Przechowywanie: Artefakty przechowywane w dedykowanym, szyfrowanym storage (evidence locker) z integrity chain. Retencja: 1 rok (STANDARD/PRO), 5 lat (STATE). Dostęp: SOC + admin-security + audytor.

Chain of custody: Każdy dostęp do artefaktów logowany. Artefakty nie mogą być modyfikowane — append-only.

50.9. Rejestr playbooków

Status: [N] Normatywny Odbiorca: SOC, Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 50.1, 50.4, 50.10

Playbooki IR to zdefiniowane procedury dla typowych scenariuszy incydentów:

Rejestr playbooków (excerpt): | ID | Nazwa | Trigger | Severity | |—|—|—| | PB-001 | Kompromitacja terminala | Device non-compliant + anomaly | HIGH | | PB-002 | Kompromitacja routera | Config drift alert | CRITICAL | | PB-003 | Kompromitacja workloadu | Malware detection / anomalous egress | HIGH | | PB-004 | Kompromitacja G1 | Integrity alert on G1 | CRITICAL | | PB-005 | Kompromitacja G2 | Integrity alert on G2 | CRITICAL | | PB-006 | DDoS na G1 | Rate limiting triggered | MEDIUM/HIGH | | PB-007 | Wyciek danych (exfiltration) | DLP alert / anomalous export | CRITICAL | | PB-008 | Operator duress | Duress signal received | HIGH | | PB-009 | Lost/stolen terminal | Operator report | HIGH | | PB-010 | Insider threat | UEBA anomaly + investigation | CRITICAL |

Każdy playbook zawiera: trigger conditions, step-by-step procedure, roles (who does what), SLA, escalation path, communication template. Playbooki są wersjonowane, reviewowane co 90 dni, i testowane (tabletop exercises) co 180 dni.

50.10. Pipeline lessons learned

Status: [N] Normatywny Odbiorca: SOC, Management Wpływ na baseline: Średni Powiązane rozdziały: 50.4, 50.9, 46.8

Po zamknięciu incydentu — obowiązkowy post-incident review:

Raport post-incident: 1. Executive summary: Kto, co, kiedy, impact 2. Timeline: Chronologiczna lista zdarzeń (50.7) 3. Root Cause Analysis (RCA): Przyczyna główna, przyczyny składowe 4. Impact assessment: Dane dotknięte, operatorzy dotknięci, downtime 5. Response assessment: Co zadziałało, co nie zadziałało, czas reakcji vs. SLA 6. Recommendations: Zmiany w politykach, infrastrukturze, procedurach 7. Action items: Konkretne zadania z przypisanymi osobami i deadlineami

Pipeline: 1. Post-incident review (meeting): 72h od zamknięcia incydentu 2. Raport: 5 dni roboczych od review 3. Action items: tracking w systemie ticketowym 4. Aktualizacja playbooków: 14 dni od zamknięcia 5. Verification: action items wykonane → weryfikacja przez admin-security

Blameless culture: Post-incident review skupia się na procesach i systemach, nie na obwinianiu osób. Cel: uczyć się i zapobiegać, nie karać.

Rozdział 51. Profile tierów i moduły specjalne

51.1. Profil STANDARD

Status: [N] Normatywny Odbiorca: Operator, Administrator, Sprzedaż Wpływ na baseline: Krytyczny Powiązane rozdziały: 32.14, 36.3, 51.10

Profil STANDARD (400 €/miesiąc/operator) jest bazowym tierem platformy SYLION:

Funkcje: - Terminale: Pixel + desktop (1 urządzenie per operator) - Router dostępowy: GL-iNet MT-3000 (w zestawie hardware kit: router 150 €, Pixel 900 €, FIDO2 200 €) - Tunel: IPsec IKEv2 (AES-256-GCM, ECP-384) - Workloady: env-matrix, env-browser, env-office - Izolacja: rootless containers (38.3) - Matrix: Synapse homeserver, E2EE domyślne - CDR: open source (DocBleach + mat2) - Export: zablokowany (clipboard, file download, print) - MFA: FIDO2 wymagany - MDM: SaaS dozwolony (EOG)

Ograniczenia vs PRO: - Brak env-signal, env-crm, env-voice - Brak eksportu plików na terminal - Brak clipboard out - Brak drukowania - Max. 1 urządzenie per operator - Izolacja kontenerowa (nie microVM) - Brak SIP/PSTN - Brak AI services

Wymagania sprzętowe: - Hardware kit: ~1250 € (jednorazowy koszt) - Łącze internetowe: min. 10 Mbps upload

51.2. Profil PRO

Status: [N] Normatywny Odbiorca: Operator, Administrator, Sprzedaż Wpływ na baseline: Krytyczny Powiązane rozdziały: 51.1, 51.3, 51.10

Profil PRO (1500 €/miesiąc/operator) rozszerza STANDARD:

Dodatki vs STANDARD: - Workloady: + env-signal, env-crm, env-voice - Izolacja: Firecracker microVM per workload (38.4) - Export: dozwolony (po CDR + DLP + watermark) - Clipboard out: tekst, max 4 KB - Print: dozwolony (po CDR + watermark) - Max. 2 urządzenia per operator - VoIP: wewnętrzny + federacyjny + SIP (opcjonalny) - CDR: komercyjny (OPSWAT / Votiro) + open source - AI services: opcjonalne (LLM, anomaly detection) - Konferencje: audio + video (720p, 25 uczestników) - Matrix: Dendrite rekomendowany - Bridges: opcjonalne (allowlist)

Przypadki użycia: - Firmy średnie i duże (20–200 operatorów) - Kancelarie prawne, firmy konsultingowe - Organizacje z wymaganiami compliance (ISO 27001, NIS2)

51.3. Profil STATE LEVEL

Status: [N] Normatywny Odbiorca: Decydent, Architekt, Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 51.1, 51.2, 51.10

Profil STATE (2500+ €/miesiąc/operator, minimum 50 operatorów) zapewnia pełną suwerenność:

Dodatki vs PRO: - Izolacja: Firecracker microVM + AMD SEV-SNP / Intel TDX (confidential computing) - HSM: FIPS 140-3 Level 3 (on-prem lub dedykowany cloud) - PKI: dedykowana CA, key ceremonies - Matrix: Dendrite, sovereign deployment, brak federacji (domyślnie) - CDR: dual engine (dwa niezależne komercyjne) - Export: domyślnie zablokowany (wyjątki per operator, dual auth) - Max. 3 urządzenia per operator (dedykowane) - Duress: wymagane (PIN, gesture, panic button) - Geofencing: wymagane - MDM: on-premise lub dedykowana instancja - SIEM: dedykowany, z retention 5 lat - Playbooki IR: customowe, testowane co 90 dni - Professional services: dedykowany account manager, support 24/7

Przypadki użycia: - Instytucje rządowe, agencje bezpieczeństwa - Infrastruktura krytyczna (energia, transport, telekomunikacja) - Organizacje wojskowe i wywiadowcze - Ambasad, przedstawicielstwa dyplomatyczne

Minimum 50 operatorów — tier STATE wymaga dedykowanej infrastruktury, co jest ekonomicznie uzasadnione od 50 operatorów. Poniżej 50 — rozważenie PRO z modułami premium (51.7).

51.4. Profil SMB/lightweight

Status: [O] Opcjonalny Odbiorca: Sprzedaż, Decydent Wpływ na baseline: Niski Powiązane rozdziały: 51.1, 51.10

Profil SMB (Small and Medium Business) jest uproszczoną wersją STANDARD dla małych organizacji (1–10 operatorów):

Uproszczenia: - Współdzielona infrastruktura (multi-tenant, nie dedicated) - Uproszczony onboarding (self-service portal) - Ograniczony support (email + FAQ, bez dedykowanego SLA) - Cena: rozważana niższa niż 400 €/operator (bundle pricing)

Ograniczenia: - Brak custom policies (standardowe polityki OPA) - Brak custom workloadów - Brak federacji Matrix (wyłącznie wewnątrz tenanta)

Profil SMB jest planowany — nie jest częścią bieżącego baseline.

51.5. Profile branżowe (Industry Profiles)

Status: [O] Opcjonalny Odbiorca: Sprzedaż, Architekt Wpływ na baseline: Niski Powiązane rozdziały: 51.1, 51.2, 51.3

Profile branżowe to predefiniowane konfiguracje SYLION dla specyficznych sektorów:

Profil	Sektor	Baza	Dodatki
Legal	Kancelarie prawne	PRO	DLP rozszerzony, legal hold, retention 7 lat
Healthcare	Opieka zdrowotna	PRO	HIPAA compliance, encrypted PHI storage
Finance	Bankowość/finanse	STATE	PCI DSS compliance, transaction logging
Defense	Obronność	STATE	PQC, CC certification, air-gap support
Critical Infrastructure	Infrastruktura krytyczna	STATE	NIS2 compliance, OT isolation

Profile branżowe są budowane na bazie tierów (STANDARD/PRO/STATE) z dodatkową konfiguracją per sektor.

51.6. Profile suwerenne (Sovereign Profiles)

Status: [O] Opcjonalny Odbiorca: Decydent, Architekt (STATE) Wpływ na baseline: Wysoki Powiązane rozdziały: 39.9, 41.10, 51.3

Profil suwerenny to konfiguracja SYLION zapewniająca pełną niezależność od dostawców zewnętrznych:

Wymagania: - Infrastruktura: on-premise w krajowym datacenter (lub sovereign cloud — OVHcloud, T-Systems) - HSM: on-premise (FIPS 140-3 Level 3) - Matrix: sovereign deployment, brak federacji (domyślnie) - DNS: własne serwery DNS (brak zależności od publicznych) - Brak zależności od: AWS/Azure/GCP (dla core services), Signal, Google Play - Update: self-hosted artifact registry, self-built firmware - Jurysdykcja: pełna kontrola nad danymi w wybranej jurysdykcji

Dodatkowe komponenty: - Własny TURN/STUN server (brak zewnętrznych) - Własny SIP gateway (brak zewnętrznych) - Własny mail relay (brak zewnętrznych) - Dedykowany team SYLION na miejscu (professional services)

51.7. Moduły premium (PQC, CC, Dark-Matrix, offline fallback)

Status: [O] Opcjonalny / [E] Eksperymentalny Odbiorca: Architekt, Decydent Wpływ na baseline: Średni Powiązane rozdziały: 34.2, 39.10, 47.1

Moduły premium to rozszerzenia wykraczające poza baseline, dostępne jako add-on:

[O] PQC (Post-Quantum Cryptography): - ML-KEM-768 (Kyber) jako dodatkowy key agreement w IKEv2 (hybrid — 34.2) - ML-DSA-65 (Dilithium) jako dodatkowy algorytm podpisu (hybrid — certyfikaty) - Cel: ochrona przed przyszłymi komputerami kwantowymi (harvest now, decrypt later) - Status: draft-ietf-ipsecme-ikev2-pqc, strongSwan z pluginem PQC

[O] CC (Common Criteria): - Proces certyfikacji Common Criteria (EAL2+ lub EAL4+) dla wybranych komponentów - Wymagany dla niektórych klientów rządowych - Dodatkowy koszt i czas (12–24 miesiące)

[E] Dark-Matrix (39.10): - Matrix homeserver dostępny wyłącznie przez Tor lub dedykowany VPN - Brak publicznego endpointu - Eksperymentalny — wymaga R&D

[O] Offline Fallback: - Tryb pracy offline z ograniczoną funkcjonalnością - Lokalna cache wiadomości Matrix (zaszyfrowana, limitowany rozmiar) - Synchronizacja po przywróceniu łączności - Złożoność: conflict resolution, data integrity - Status: koncepcyjny, wymaga R&D

51.8. Moduły autonomiczne [A]

Status: [A] Autonomiczny Odbiorca: Architekt, Administrator (zaawansowany) Wpływ na baseline: Niski (niezależne od baseline) Powiązane rozdziały: 33.15, 34.9, 51.7

Moduły autonomiczne rozszerzają SYLION poza standardowy baseline — dla zaawansowanych scenariuszy operacyjnych:

Lista modułów autonomicznych: | ID | Moduł | Opis | Rozdział | |---|---|---| | A-01 | IMEI/IMSI monitoring | Detekcja anomalii sieci komórkowej | 33.15 | | A-02 | Starlink support | Łączność satelitarna | 33.15 | | A-03 | BTS forcing detection | Detekcja fałszywych stacji bazowych | 33.15 | | A-04 | Multi-WAN failover | Automatyczne przełączanie łączy | 33.15 | | A-05 | Mesh networking | Komunikacja peer-to-peer między routerami | Nowy | | A-06 | Custom workloads | Dedykowane workloady per organizacja | 38.4 | | A-07 | Hardware tokens (custom) | Dedykowane tokeny sprzętowe | 44.11 |

Moduły autonomiczne nie są objęte standardowym wsparciem. Wdrożenie wymaga professional services.

51.9. Moduły eksperymentalne [E]

Status: [E] Eksperymentalny Odbiorca: Architekt (R&D) Wpływ na baseline: Niski (nie w produkcji) Powiązane rozdziały: 37.16, 41.11, 51.7

Moduły eksperymentalne to koncepcje badane przez R&D SYLION, nie przeznaczone do produkcji:

ID	Moduł	Opis	Status
E-01	Blind Broker	Session Broker bez dostępu do treści	R&D (37.16)
E-02	SFrame E2EE media	Szyfrowanie per-frame audio/video	R&D (41.11)
E-03	Dark-Matrix	Matrix over Tor	Koncepcja (39.10)
E-04	IPsec obfuscation	Maskowanie ruchu IPsec jako HTTPS	Koncepcja (34.12)
E-05	Offline Matrix cache	Praca offline z synchronizacją	Koncepcja (51.7)
E-06	Federated AI	AI models federated across tenants	Koncepcja
E-07	Zero-knowledge proof auth	ZKP dla uwierzytelnienia	Badawczy

Moduły eksperymentalne mogą zostać włączone do baseline w przyszłych wersjach SYLION po walidacji produkcyjnej.

51.10. Macierz funkcji per tier (pełna tabela)

Status: [N] Normatywny Odbiorca: Wszyscy Wpływ na baseline: Krytyczny Powiązane rozdziały: 51.1, 51.2, 51.3

Pełna macierz funkcji SYLION 3.0:

Funkcja	STANDARD (400€)	PRO (1500€)	STATE (2500€+)	Status
Terminale				
Pixel (referencyjny)	✓	✓	✓	[N]
Desktop/laptop	✓	✓	✓ (dedykowany)	[N]
Max urządzeń/operator	1	2	3	[N]
Sieć				
Router GL-iNet MT-3000	✓	✓	✓ (lub APU4)	[N]
IPsec IKEv2 (AES-256-GCM)	✓	✓	✓ (FIPS)	[N]
Kill switch	✓	✓	✓	[N]
PQC hybrid	X	Opcja	Opcja	[O]
Multi-WAN failover	Opcja	✓	✓	[R]
Workloady				
env-matrix	✓	✓	✓	[N]
env-browser	✓	✓	✓	[N]
env-office	✓	✓	✓	[N]
env-signal	X	✓	✓	[N]
env-crm	X	✓	✓	[N]
env-voice	X	✓	✓	[N]
env-custom	X	Opcja	✓	[O]
Izolacja				
Rootless containers	✓	X	X	[N]

Firecracker microVM	X	✓	✓	[N]
AMD SEV-SNP / Intel TDX	X	X	✓	[N]
Komunikacja				
Matrix (wewnętrzny)	✓	✓	✓	[N]
Matrix (federacja)	Allowlist	Allowlist	Per polityka	[N]
Signal (kompatybilność)	X	✓	✓	[N]
VoIP (wewnętrzny)	Audio	Audio + Video	Audio + Video HD	[N]
SIP/PSTN	X	Opcja	✓	[O]
Konferencje	Audio 50	Video 720p/25	Video 1080p/10	[R]
Bezpieczeństwo				
MFA FIDO2	✓	✓	✓	[N]
CDR (open source)	✓	✓	✓	[N]
CDR (komercyjny)	X	✓	✓ (dual)	[N]
DLP	X	✓	✓	[R]
HSM	Cloud	Cloud	On-prem (FIPS L3)	[N]
Geofencing	X	Opcja	✓	[N]
Duress functions	X	Rekomendowane	✓	[R/N]
Export				
File download	Zablokowany	Po CDR/DLP	Wyjątki (dual auth)	[N]
Clipboard out	Zablokowany	Tekst 4 KB	Zablokowany	[N]
Print	Zablokowany	Po CDR + watermark	Dual auth	[N]
Screen capture	FLAG_SECURE	FLAG_SECURE + watermark	FLAG_SECURE + watermark	[N]
Admin				
MDM	SaaS (EOG)	SaaS / On-prem	On-prem	[N]
SIEM	Współdzielony	Współdzielony / Dedykowany	Dedykowany	[N]
Dual authorization	Wybrane op.	Rekomendowane	Wymagane	[N]
JIT admin access	✓	✓	✓	[N]
Session recording	✓	✓	✓	[N]
Policy engine (OPA)	✓	✓	✓	[N]
AI/ML				
Anomaly detection	X	Opcja	✓	[R]
LLM services	X	Opcja	Opcja	[O]
AI triage	X	Opcja	✓	[R]
Specjalne				
Sovereign deployment	X	X	✓	[O]
Common Criteria	X	X	Opcja	[O]
Dark-Matrix	X	X	Opcja	[E]
Offline fallback	X	X	Opcja	[E]
Professional services	Brak	Opcja	Dedykowany	[N]
Min. operatorów	1	1	50	[N]
Cena hardware kit	~1250 €	~1250 €	~1500 €	[N]
Cena miesięczna/operator	400 €	1500 €	2500+ €	[N]

Koniec Części V — Moduły systemowe i szczegółowe specyfikacje (Rozdziały 32–51)

CZĘŚĆ VI — API, KONTRAKTY, DANE I INTERFEJSY

Rozdział 52. Zasady projektowania API

52.1 REST, GraphQL, gRPC — kiedy każdy styl jest dopuszczalny w kontekście SYLION

Status: [N] Normatywny Odbiorca: Architekt, Backend Developer, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 53.1, 54.1, 55.1

W ekosystemie SYLION 3.0 współistnieją trzy style komunikacji API, z których każdy pełni ściśle określoną rolę wynikającą z charakterystyki architektonicznej platformy — modelu Zero Trust, podziału na strefy (Zone 0–5) oraz wymagań dotyczących wydajności i bezpieczeństwa.

REST (Representational State Transfer) stanowi domyślny styl API dla wszystkich interfejsów zewnętrznych (public-facing), panelu administratora, integracji partnerskich oraz komunikacji między strefami Zone 1 (access) i Zone 4 (shared services). REST musi być stosowany wszędzie tam, gdzie interoperacyjność z systemami zewnętrznymi jest priorytetem — w tym w integracjach z SIEM/SOAR, systemami ITSM, ERP/CRM oraz w API dostępnym dla certyfikowanych integratorów. Każdy endpoint REST musi być udokumentowany za pomocą specyfikacji OpenAPI 3.1+. REST w SYLION wymaga stosowania JSON jako formatu danych (z wyjątkiem endpointów binarnych), nagłówków bezpieczeństwa zgodnych z OWASP API Security Top 10, oraz pełnej idempotentności dla operacji mutujących.

gRPC jest preferowanym stylem komunikacji wewnętrznej między mikroservisami w obrębie tej samej strefy (intra-zone), szczególnie w Zone 3 (workloads) i Zone 5 (management). gRPC oparte na HTTP/2 i Protocol Buffers zapewnia typowanie kontraktów, niską latencję i efektywne wykorzystanie łącza — co jest krytyczne dla komunikacji między session brokerem, policy engine, silnikiem CDR oraz modułami zarządzania mikroVM. gRPC musi być stosowany z mTLS (mutual TLS) opartym na tożsamościach SPIFFE/SVID. Streaming gRPC (bidirectional) jest dopuszczalny wyłącznie dla telemetrii runtime, logów strumieniowych oraz komunikacji z eBPF collectors.

GraphQL jest dozwolony wyłącznie w ściśle określonych scenariuszach: panel developerski (developer portal), dashboard operatorski wymagający agregacji danych z wielu źródeł oraz narzędzia analityczne (OLAP). GraphQL nie może być eksponowany na zewnątrz bez dedykowanego gateway'a z rate limitingiem, ograniczeniem głębokości zapytań (max depth: 5), limitem złożoności (max complexity: 500) i timeout'em (max 10s). GraphQL nie jest dopuszczalny dla operacji administracyjnych, krytycznych dla bezpieczeństwa ani dla interfejsów wymagających zgodności z normami FIPS/CC.

Każdy nowy endpoint musi przejść przegląd architektury (Architecture Review Board — ARB), który weryfikuje zgodność wybranego stylu z matrycą decyzyjną opisaną w 52.2.

52.2 Kiedy który styl jest dozwolony — matryca decyzyjna

Status: [N] Normatywny Odbiorca: Architekt, Backend Developer, Product Owner Wpływ na baseline: Krytyczny Powiązane rozdziały: 52.1, 53.2, 56.1

Matryca decyzyjna definiuje obowiązkowy algorytm wyboru stylu API na podstawie pięciu wymiarów: typ konsumenta, strefa sieciowa, wymagania wydajnościowe, wymagania bezpieczeństwa i złożoność danych.

Wymiar	REST	gRPC	GraphQL
Konsument zewnętrzny (partner, SIEM, ITSM)	✅ Wymagany	❌ Niedozwolony	❌ Niedozwolony
Konsument wewnętrzny (mikroservis w tej samej strefie)	⚠️ Dozwolony ✅ P r	edezrowany ❌ N i	edozwolony
Konsument wewnętrzny (cross-zone)	✅ Wymagany	⚠️ Dozwolony z ❌ i N mTLS	edozwolony
Panel administratora	✅ Wymagany	❌ Niedozwolony	❌ Niedozwolony
Developer portal / dashboard	✅ Dozwolony	❌ Niedozwolony	✅ Dozwolony
Telemetria / streaming	❌ Nieefektywny	✅ Wymagany	❌ Niedozwolony
Operacje krytyczne bezpieczeństwa	✅ Wymagany	✅ Dozwolony	❌ Zabroniony
Mobile / thin client	✅ Wymagany	❌ Niedozwolony	⚠️ Dozwolony za zgodą ARB

Procedura decyzyjna:

Jeśli konsument jest zewnętrzny → REST (bezwzględnie).

Jeśli komunikacja jest wewnętrzna intra-zone i wymaga niskiej latencji → gRPC.

Jeśli komunikacja jest cross-zone → REST domyślnie; gRPC dozwolony po audycie mTLS.

Jeśli operacja jest destrukcyjna (delete, revoke, wipe) → REST z logowaniem Four-Eyes.

Jeśli endpoint wymaga agregacji wielu zasobów w jednym zapytaniu dla UI → GraphQL za zgodą ARB.

Jeśli endpoint wymaga streaming → gRPC bidirectional.

Wyjątki wymagają pisemnego uzasadnienia w rejestrze ARB i podlegają rewizji co 6 miesięcy. Każdy wyjątek musi wskazywać: powód odejścia od matrycy, analizę ryzyka, plan migracji do preferowanego stylu (jeśli dotyczy) oraz datę przeglądu.

Naruszenie matrycy bez zatwierdzonego wyjątku stanowi defekt bezpieczeństwa kategorii P1 i blokuje deployment.

52.3 Nazewnictwo, paginacja, idempotentność — konkretne konwencje

Status: [N] Normatywny Odbiorca: Backend Developer, Architekt, QA Wpływ na baseline: Wysoki Powiązane rozdziały: 52.4, 53.5, 53.6

Konwencje nazewnictwa:

Wszystkie ścieżki REST muszą stosować notację kebab-case dla segmentów URL i camelCase dla parametrów query string oraz pól JSON. Nazwy zasobów muszą być rzeczownikami w liczbie mnogiej (np. /v2/operators, /v2/sessions, /v2/micro-vms). Czasowniki w ścieżkach są zabronione — operacje wyrażane są wyłącznie za pomocą metod HTTP. Jedyny wyjątek stanowią operacje RPC-like, które nie mapują się na CRUD (np. /v2/sessions/{id}/actions/terminate), gdzie segment actions jest wymagany prefiksem.

Nazwy pól w gRPC (Protocol Buffers) muszą stosować snake_case zgodnie z konwencją proto3. Nazwy wiadomości — PascalCase. Nazwy serwisów — PascalCase z sufiksem Service (np. PolicyEngineService).

Paginacja:

SYLION wymaga paginacji opartej na kursorze (cursor-based) dla wszystkich endpointów zwracających kolekcje. Paginacja offset-based jest zabroniona ze względu na niestabilność przy równoczesnych zapisach oraz podatność na enumerację. Format odpowiedzi:

```
{ "data": [...], "pagination": { "nextCursor": "eyJpZCI6MTAwfQ==", "previousCursor": "eyJpZCI6NTB9", "hasMore": true, "pageSize": 50 } }
```

Domyślny rozmiar strony: 50 elementów. Maksymalny: 200. Klient może żądać mniejszego rozmiaru. Cursor musi być nieprzewidywalnym tokenem (base64-encoded, zaszyfrowany symetrycznie) — nie może ujawniać wewnętrznych identyfikatorów sekwencyjnych.

Idempotentność:

Wszystkie operacje mutujące (POST, PUT, PATCH, DELETE) muszą obsługiwać nagłówek Idempotency-Key. Klient generuje UUID v4 i przysyła go w nagłówku. Serwer musi:

Sprawdzić, czy klucz był już przetwarzany (lookup w Redis/cache z TTL 24h).

Jeśli tak — zwrócić oryginalną odpowiedź bez ponownego wykonania operacji.

Jeśli nie — wykonać operację i zapisać wynik z kluczem.

Przy konflikcie (ten sam klucz, inne body) — zwrócić HTTP 422 Unprocessable Entity.

Operacje GET i HEAD są z natury idempotentne i nie wymagają klucza. Operacje DELETE muszą być idempotentne — powtórne DELETE na nieistniejącym zasobie zwraca 204 No Content (nie 404).

52.4 Projektowanie zasobów — hierarchia, struktura URL, metody HTTP

Status: [N] Normatywny Odbiorca: Backend Developer, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 52.3, 53.1, 55.7

Hierarchia zasobów w SYLION odzwierciedla model domenowy platformy z wyraźnym podziałem na konteksty bounded (DDD):

```
/v2/operators/{operatorId} /v2/operators/{operatorId}/environments/{envId} /v2/operators/{operatorId}/environments/{envId}/sessions/{sessionId}
/v2/operators/{operatorId}/environments/{envId}/workloads/{workloadId} /v2/policies/{policyId} /v2/audit-logs /v2/certificates/{certId}
/v2/integrations/{integrationId}
```

Maksymalna głębokość zagnieżdżenia: 3 poziomy (np. /operators/{id}/environments/{id}/sessions/{id}). Głębsze relacje muszą być wyrażane jako top-level resources z referencjami (np. /v2/workloads/{id} zamiast /operators/{id}/environments/{id}/workloads/{id}/processes/{id}).

Struktura URL:

Bazowy URL: https://api.sylon.{domain}/v{major}/. Wersja jest częścią ścieżki (URI versioning — patrz 54.1). Środowiska (sandbox, staging, production) rozróżniane są przez subdomenę, nie przez ścieżkę.

Metody HTTP i ich semantyka:

Metoda	Semantyka	Kod sukcesu	Idempotentna	Wymaga Idempotency-Key
GET	Odczyt zasobu/kolekcji	200	Tak (naturalnie)	Nie
POST	Tworzenie nowego zasobu	201 + Location header	Nie	Tak
PUT	Pełna aktualizacja zasobu	200 lub 204	Tak	Tak (rekomendowane)
PATCH	Częściowa aktualizacja (JSON Merge Patch)	200	Nie	Tak
DELETE	Usunięcie zasobu	204	Tak	Tak (rekomendowane)

Operacje destrukcyjne (DELETE na krytycznych zasobach: operator, environment, certyfikat root) wymagają nagłówka X-Four-Eyes-Approval zawierającego podpis drugiego administratora (zgodnie z zasadą dual authorization). Serwer musi zweryfikować podpis przed wykonaniem operacji.

Filtry i sortowanie:

Filtry przekazywane jako parametry query string: ?status=active&tier=PRO&createdAfter=2026-01-01T00:00:00Z. Sortowanie: ?sort=createdAt:desc,name:asc. Pola filtrów i sortowania muszą być jawnie zadeklarowane w specyfikacji OpenAPI — nieznanne pola powodują HTTP 400.

52.5 API sterowane zdarzeniami — wzorce asynchroniczne, schematy zdarzeń

Status: [N] Normatywny Odbiorca: Backend Developer, Architekt, DevSecOps Wpływ na baseline: Wysoki Powiązane rozdziały: 52.6, 53.4, 58.1

Platforma SYLION generuje zdarzenia domenowe (domain events), które stanowią kluczowy mechanizm komunikacji asynchronicznej między mikroserwisami oraz podstawę audytowalności systemu. Każde zdarzenie musi być zgodne z formatem CloudEvents 1.0.2, zapewniając interoperacyjność z zewnętrznymi systemami SIEM/SOAR.

Struktura zdarzenia:

```
{ "specversion": "1.0", "id": "550e8400-e29b-41d4-a716-446655440000", "source": "urn:sylon:zone3:policy-engine", "type": "com.sylon.session.terminated",
"datacontenttype": "application/json", "time": "2026-04-05T14:28:00.000Z", "subject": "session/abc-123", "sylonzone": "3", "sylonoperator": "op-456",
```

"sylionsecuritylevel": "HIGH", "data": { "sessionId": "abc-123", "reason": "POLICY_VIOLATION", "terminatedBy": "policy-engine", "operatorId": "op-456" } }

Rozszerzenia SYLION: Każde zdarzenie musi zawierać atrybuty rozszerzeń: sylionzone (strefa źródłowa), sylionoperator (identyfikator operatora, jeśli dotyczy), sylionsecuritylevel (LOW/MEDIUM/HIGH/CRITICAL). Zdarzenia oznaczone jako CRITICAL muszą być dostarczane synchronicznie do modułu alertingu (bypass kolejki).

Kategorie zdarzeń:

Zdarzenia sesyjne: session.created, session.terminated, session.timeout, session.policy-violation

Zdarzenia workload: workload.started, workload.stopped, workload.health-check-failed, workload.breakout-detected

Zdarzenia bezpieczeństwa: security.auth-failure, security.cert-rotated, security.policy-updated, security.intrusion-detected

Zdarzenia operacyjne: operator.created, operator.suspended, operator.tier-changed

Zdarzenia audytowe: audit.admin-action, audit.four-eyes-approved, audit.evidence-exported

Gwarancje dostarczenia: System musi zapewniać semantykę at-least-once. Konsumenci muszą być idempotentni. Kolejność zdarzeń jest gwarantowana w obrębie partycji (partition key = operatorId). Zdarzenia muszą być retencjonowane w brokerze przez minimum 72 godziny.

52.6 API asynchroniczne — wzorce kolejkowe, webhook patterns

Status: [N] Normatywny Odbiorca: Backend Developer, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 52.5, 52.7, 58.1

Wzorce kolejkowe:

SYLION stosuje broker wiadomości (Apache Kafka lub NATS JetStream — wybór per-deployment) jako centralny bus zdarzeń. Topologia kolejek odzwierciedla podział na strefy bezpieczeństwa:

Klaster per-zone: Każda strefa (Zone 3, Zone 4, Zone 5) posiada dedykowany klaster brokera. Komunikacja cross-zone odbywa się wyłącznie przez dedykowane bridge'e z mTLS i filtrowaniem tematów.

Topic naming: sylion.{zone}.{domain}.{eventType} (np. sylion.zone3.session.terminated). Tematy są predefiniowane — dynamiczne tworzenie tematów jest zabronione.

Partycjonowanie: Klucz partycji = operatorId, zapewniający kolejność zdarzeń per-operator. Wyjątek: zdarzenia globalne (np. security.platform-alert) używają klucza ALL.

Consumer groups: Każdy mikroservis konsumuje zdarzenia w ramach named consumer group. Duplikacja (fan-out) realizowana przez osobne consumer groups, nie przez kopiowanie wiadomości.

Wzorec Request-Reply asynchroniczny:

Dla operacji wymagających asynchronicznego przetwarzania (np. provisioning microVM, generowanie certyfikatu, skanowanie CDR), SYLION stosuje wzorec Async Request-Reply:

Klient wysyła POST → serwer zwraca HTTP 202 Accepted z nagłówkiem Location: /v2/operations/{operationId}.

Klient odpytuje (poll) endpoint /v2/operations/{operationId} — status: PENDING, IN_PROGRESS, COMPLETED, FAILED.

Alternatywnie: klient rejestruje webhook (patrz 52.7) i otrzymuje callback po zakończeniu.

Dead Letter Queue (DLQ):

Zdarzenia, których przetworzenie nie powiodło się po 5 próbach (z exponential backoff: 1s, 5s, 30s, 5min, 30min), trafiają do DLQ. DLQ jest monitorowany przez SOC — zdarzenia w DLQ mogą wskazywać na atak lub awarię. Reprocessing z DLQ wymaga manualnej autoryzacji operatora SOC.

Backpressure:

Konsumenci muszą implementować mechanizm backpressure. Jeśli konsument nie przetwarza zdarzeń przez 15 minut, broker wstrzymuje dostarczanie i generuje alert. Brak backpressure stanowi defekt bezpieczeństwa — niekontrolowane zaległości mogą prowadzić do utraty zdarzeń audytowych.

52.7 Webhooks — wymagania bezpieczeństwa, podpisywanie, retry

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps, Partner Integration Wpływ na baseline: Wysoki Powiązane rozdziały: 52.5, 52.6, 55.1

Webhooks w SYLION służą do powiadamiania zewnętrznych systemów (SIEM, ITSM, CRM, partnerskie platformy) o zdarzeniach platformy. Każdy webhook musi spełniać rygorystyczne wymagania bezpieczeństwa.

Rejestracja webhook:

Operator rejestruje webhook endpoint poprzez API: POST /v2/webhooks z body zawierającym url, events (lista typów zdarzeń), secret (opcjonalnie — jeśli nie podany, system generuje 256-bitowy secret). URL musi być HTTPS (HTTP jest zabroniony). System weryfikuje ownership URL przez wysłanie challenge request (POST z challenge token — endpoint musi zwrócić token w odpowiedzi).

Podpisywanie (Signing):

Każdy webhook request jest podpisywany za pomocą HMAC-SHA-256. Nagłówki:

X-Sylon-Signature: sha256=<hex-encoded HMAC> X-Sylon-Timestamp: 1712345678 X-Sylon-Delivery-Id: <UUID>

Obliczanie HMAC: HMAC-SHA256(secret, timestamp + "." + body). Odbiorca musi:

Zweryfikować podpis HMAC.

Sprawdzić, czy timestamp nie jest starszy niż 5 minut (ochrona przed replay attack).

Sprawdzić unikalność Delivery-Id (ochrona przed duplikacją).

Retry policy:

Próba	Opóźnienie	Timeout
1 (oryginalna)	0s	10s
2	30s	10s
3	5 min	10s
4	30 min	10s
5	2 godz.	10s
6	12 godz.	10s

Po 6 nieudanych próbach webhook jest oznaczany jako FAILING. Po 72 godzinach ciągłych błędów — automatycznie dezaktywowany. Operator otrzymuje powiadomienie po 3. próbie i przy dezaktywacji.

Bezpieczeństwo dodatkowe:

Webhook URL nie może wskazywać na adresy wewnętrzne (RFC 1918, loopback, link-local) — ochrona przed SSRF.

Payload webhooków nie zawiera wrażliwych danych (secrets, tokens, treści wiadomości) — jedynie identyfikatory i metadane. Odbiorca musi pobrać szczegóły przez API z autoryzacją.

Rate limit: max 100 webhook deliveries/min per operator. Przy przekroczeniu — buforowanie z opóźnionym dostarczeniem.

Webhook secret można rotować bez downtime'u: system obsługuje dwa aktywne sekrety jednocześnie (primary + rollover) przez okres 24h.

52.8 Wzorce integracji — adapter, gateway, warstwa antykorupcyjna

Status: [N] Normatywny Odbiorca: Architekt, Backend Developer, Integration Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 59.1, 59.10, 61.1

SYLION jako platforma komunikacyjna musi integrować się z ekosystemem zewnętrznym (IdP, SIEM, ITSM, ERP, płatności) przy jednoczesnym zachowaniu integralności modelu domenowego i granic bezpieczeństwa. Trzy wzorce integracji stanowią obowiązkowy arsenał architektoniczny.

Wzorzec Adapter:

Adapter tłumaczy interfejs systemu zewnętrznego na wewnętrzny interfejs SYLION. Każdy adapter jest osobnym mikroserwisem deployowanym w Zone 4 (shared services) z ograniczonym dostępem sieciowym wyłącznie do docelowego systemu zewnętrznego i wewnętrznego konsumenta. Adaptery muszą:

Implementować Circuit Breaker (próg: 5 błędów / 60s → open state na 30s).

Logować wszystkie wywołania zewnętrzne (request/response sans sensitive data) do audit log.

Posiadać health check endpoint zwracający status connectivity z systemem zewnętrznym.

Być stateless — stan integracji przechowywany w zewnętrznym store (Redis/PostgreSQL).

Przykłady adapterów: okta-adapter, splunk-adapter, servicenow-adapter, azure-ad-adapter.

Wzorzec API Gateway:

SYLION wymaga dedykowanego API Gateway (np. Kong, Envoy-based) deployowanego na granicy Zone 1/Zone 2. Gateway odpowiada za:

Terminację TLS — certyfikaty zarządzane przez Vault PKI.

Uwierzytelnianie — weryfikacja tokenów JWT, walidacja mTLS dla partnerów.

Rate limiting — per-client, per-endpoint (patrz 56.1).

Routing — kierowanie requestów do odpowiednich mikroserwisów w Zone 3/4.

Transformacja — header injection (X-Operator-Id, X-Zone, X-Request-Id), stripping wewnętrznych nagłówków.

CORS — konfiguracja per-origin, nigdy Access-Control-Allow-Origin: *.

WAF — integracja z Web Application Firewall (OWASP CRS).

Gateway nie może modyfikować body requestu (transparentny proxy). Wyjątek: CDR scanning pipeline, gdzie gateway deleguje przetwarzanie do inline CDR engine.

Warstwa antykorupcyjna (Anti-Corruption Layer — ACL):

ACL jest obowiązkowa wszędzie tam, gdzie model danych systemu zewnętrznego jest niezgodny z modelem domenowym SYLION. ACL tłumaczy koncepcje, nazewnictwo i semantykę między systemami. Przykład: system ITSM operuje pojęciem „ticket”, SYLION operuje pojęciem „incident” — ACL mapuje pola, statusy i workflow. ACL jest implementowana jako dedykowany moduł w warstwie adaptera — nie w logice domenowej. ACL musi posiadać testy kontraktowe weryfikujące poprawność mapowania przy każdej zmianie w API zewnętrznym.

Rozdział 53. Standardy kontraktów

i formatów danych

53.1 JSON Schema — wersjonowanie, walidacja, reguły kompatybilności

Status: [N] Normatywny Odbiorca: Backend Developer, Architekt, QA Wpływ na baseline: Krytyczny Powiązane rozdziały: 53.2, 54.1, 57.1

JSON Schema (draft 2020-12) stanowi obowiązkowy mechanizm definiowania i walidacji kontraktów danych w SYLION dla wszystkich interfejsów REST i webhook. Każdy kontrakt musi posiadać schemat JSON Schema przechowywany w centralnym rejestrze schematów (Schema Registry).

Wersjonowanie schematów:

Każdy schemat posiada wersję semantyczną (SemVer) powiązaną z wersją API. Schematy są identyfikowane przez URI: <https://schema.sylion.io/v2/session.schema.json>. Zmiany schematu podlegają klasyfikacji:

Kompatybilne wstecz (backward-compatible): dodanie opcjonalnego pola, rozszerzenie enum o nową wartość (z zachowaniem starych) — minor version bump.

Niekompatybilne (breaking): usunięcie pola, zmiana typu pola, zmiana z opcjonalnego na wymagany, zawężenie enum — major version bump, wymagający nowej wersji API.

Reguły walidacji:

Walidacja JSON Schema musi odbywać się na trzech poziomach:

API Gateway (Zone 1): walidacja strukturalna (format, typy, wymagane pola) — odrzucenie malformed requestów przed dotarciem do mikroserwisu. Walidacja musi być performant — timeout max 5ms.

Mikroservis (Zone 3/4): walidacja semantyczna (business rules, cross-field validation) — implementowana w logice serwisu.

Event broker: walidacja schematów zdarzeń przed publikacją do topicu (schema-on-write).

Reguły kompatybilności:

SYLION wymaga kompatybilności wstecznej (backward compatibility) jako domyślnej. Oznacza to, że nowa wersja schematu musi akceptować dane zgodne ze starą wersją. Kompatybilność pełna (full compatibility — backward + forward) jest wymagana dla schematów zdarzeń audytowych, ponieważ konsumenci mogą przetwarzać zarówno stare, jak i nowe zdarzenia.

Testy kompatybilności schematów muszą być częścią pipeline'u CI/CD. Narzędzia: ajv (JavaScript), jsonschema (Python) lub odpowiedniki z kontrolą kompatybilności (np. Confluent Schema Registry compatibility checks).

Zakaz schematów otwartych: Schematy nie mogą używać `additionalProperties: true` w produkcji. Wszystkie pola muszą być jawnie zadeklarowane. Wyjątek: pola `metadata` i `extensions` typu `object` z jawnym ograniczeniem rozmiaru (max 10 kluczy, max 1KB).

53.2 OpenAPI — spec-first development, tooling, publikacja

Status: [N] Normatywny Odbiorca: Backend Developer, Architekt, Technical Writer, Partner Integration Wpływ na baseline: Krytyczny Powiązane rozdziały: 52.1, 53.1, 60.8

SYLION wymaga podejścia spec-first (specification-first) dla wszystkich API REST. Oznacza to, że specyfikacja OpenAPI 3.1+ jest tworzona i zatwierdzana przed napisaniem kodu implementacji. Specyfikacja jest źródłem prawdy (single source of truth) dla kontraktów API.

Wymagania specyfikacji:

Każda specyfikacja OpenAPI musi zawierać:

Info: tytuł, opis, wersja, kontakt, licencja.

Security schemes: OAuth 2.0, mTLS, API key — zdefiniowane globalnie, stosowane per-endpoint.

Paths: każdy endpoint z pełnym opisem, parametrami, request body (ze schematem JSON Schema), responses (wszystkie możliwe kody: 200, 201, 204, 400, 401, 403, 404, 409, 422, 429, 500, 503).

Components/schemas: wszystkie modele danych jako reusable components.

Tags: grupowanie endpointów według domeny (sessions, operators, policies, audit).

Examples: minimum jeden przykład request/response dla każdego endpointa.

Extensions: x-sylion-zone (strefa deploymentu), x-sylion-four-eyes (czy wymaga dual authorization), x-sylion-audit-level (poziom logowania audytowego).

Workflow spec-first:

Architekt/developer tworzy specyfikację OpenAPI w formacie YAML.

Specyfikacja przechodzi linting (spectral z regułami SYLION — patrz ruleset w repozytorium api-standards).

Przegląd przez ARB (Architecture Review Board) i Security Team.

Zatwierdzenie → merge do repozytorium api-specs.

Automatyczna generacja: stub serwerowy (Go/Java), klient SDK (TypeScript, Python, Go), dokumentacja (Redoc/Swagger UI).

Implementacja musi być zgodna ze specyfikacją — testy kontraktowe (Prism mock server) weryfikują zgodność.

Publikacja:

Specyfikacje są publikowane w developer portalu pod adresem <https://docs.sylion.{domain}/api/>. Każda wersja API posiada osobną dokumentację. Developer portal wymaga uwierzytelnienia — publiczny dostęp jest ograniczony do ogólnego opisu API (bez szczegółów implementacyjnych wrażliwych z perspektywy bezpieczeństwa).

Zakazy:

Generowanie specyfikacji z kodu (code-first) jest zabronione w produkcji.

Ręczne modyfikacje wygenerowanych klientów SDK są zabronione — zmiany wyłącznie przez modyfikację specyfikacji.

Specyfikacja nie może zawierać endpointów nieimplementowanych (x-sylon-status: planned dozwolony wyłącznie w branchu development).

53.3 Protobuf — kiedy stosować, wersjonowanie, kompatybilność wsteczna

Status: [N] Normatywny Odbiorca: Backend Developer, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 52.1, 53.1, 54.2

Protocol Buffers (proto3) stanowią obowiązkowy format serializacji dla komunikacji gRPC w SYLION. Protobuf jest stosowany wyłącznie w komunikacji wewnętrznej (intra-zone i cross-zone między mikroserwisami) — nigdy dla interfejsów zewnętrznych.

Kiedy stosować Protobuf:

Komunikacja gRPC między mikroserwisami w Zone 3 (session broker ↔ policy engine, CDR engine ↔ workload manager).

Komunikacja gRPC w Zone 5 (management plane — orchestrator ↔ config manager ↔ secret rotator).

Telemetria strumieniowa (streaming gRPC) — metryki z eBPF collectors, logi runtime.

Serializacja wewnętrznych zdarzeń w brokerze wiadomości (alternatywa dla Avro — patrz 53.4 dla decyzji).

Wersjonowanie Protobuf:

Pliki .proto są przechowywane w dedykowanym repozytorium proto-contracts z następującą strukturą:

```
proto-contracts/ ├── sylion/ | ├── session/v2/session.proto | ├── policy/v2/policy.proto | ├── workload/v2/workload.proto | ├── audit/v2/audit_event.proto
| └── management/v2/management.proto
```

Wersja jest częścią pakietu proto: package sylion.session.v2;. Nowa major version = nowy pakiet (v3), stary utrzymywany przez minimum 6 miesięcy.

Reguły kompatybilności wstecznej:

Obowiązkowe: - Nie usuwać pól — oznaczać jako reserved. - Nie zmieniać numerów pól istniejących. - Nie zmieniać typów pól (np. int32 → int64). - Nowe pola muszą mieć nowe numery i wartości domyślne (zero-value w proto3). - Enum: nie zmieniać numerów istniejących wartości, nowe wartości dodawać na końcu.

Walidacja (buf):

SYLION wymaga narzędzia buf do lintingu i sprawdzania breaking changes. Pipeline CI/CD uruchamia:

```
buf lint buf breaking --against '.git#branch=main'
```

Każdy PR modyfikujący pliki .proto musi przejść kontrolę breaking changes. Breaking change blokuje merge i wymaga nowej major version.

Generowanie kodu:

Kod generowany jest automatycznie przez buf generate z pluginami per-język (Go, Java, Python, TypeScript). Wygenerowany kod jest commitowany do dedykowanych repozytoriów per-język (np. proto-go, proto-java) — nie do repozytorium serwisu.

53.4 Avro i schematy zdarzeń — event streaming, rejestr schematów

Status: [R] Rekomendowany Odbiorca: Backend Developer, Architekt, Data Engineer Wpływ na baseline: Średni Powiązane rozdziały: 52.5, 53.3, 58.1

Apache Avro jest rekomendowanym formatem serializacji zdarzeń w brokerze wiadomości (Kafka/NATS) jako alternatywa dla Protobuf. Wybór między Avro a Protobuf dla event streaming jest decyzją deployment-level — oba formaty są obsługiwane, ale w danym deploymentcie musi być stosowany jeden format konsekwentnie.

Kiedy preferować Avro:

Deployment z ekosystemem Kafka (Confluent Platform) — natywna integracja z Schema Registry.

Potrzeba ewolucji schematów z wbudowanym wsparciem backward/forward/full compatibility.

Konsumenci w JVM (Java/Scala) — Avro ma najlepsze wsparcie w tym ekosystemie.

Kiedy preferować Protobuf:

Deployment z NATS JetStream — lżejsza integracja.

Spójność z komunikacją gRPC (ten sam format wewnątrz i w event bus).

Konsumenci w Go — Protobuf ma lepsze wsparcie.

Schema Registry:

Niezależnie od wybranego formatu, SYLION wymaga centralnego Schema Registry (Confluent Schema Registry lub kompatybilny — np. Apicurio). Registry przechowuje wersje schematów i wymusza kompatybilność przy publikacji nowych wersji.

Konfiguracja kompatybilności per-topic: - Zdarzenia audytowe (sylon.*.audit.*): FULL — backward + forward. - Zdarzenia sesyjne (sylon.*.session.*): BACKWARD — nowi konsumenci czytają stare zdarzenia. - Zdarzenia telemetryczne (sylon.*.telemetry.*): BACKWARD.

Rejestracja schematu:

Każdy nowy schemat zdarzenia musi być zarejestrowany w Registry przed pierwszą publikacją. Producent nie może opublikować zdarzenia z niezarejestrowanym schematem — broker odrzuci wiadomość. Rejestracja odbywa się automatycznie w pipeline CI/CD po przejściu testów kompatybilności.

ID schematu:

Każde zdarzenie w brokerze zawiera ID schematu (4-bajtowy prefix wg konwencji Confluent Wire Format). Konsument pobiera schemat z Registry na podstawie ID i deserializuje wiadomość. Cache schematów po stronie konsumenta — TTL 5 minut.

53.5 Konwencje serializacji — data/czas, enumy, pola nullable

Status: [N] Normatywny Odbiorca: Backend Developer, QA Wpływ na baseline: Wysoki Powiązane rozdziały: 53.1, 53.2, 57.1

Spójność serializacji danych jest fundamentem interoperacyjności w systemie rozproszonym. SYLION definiuje obowiązkowe konwencje dla wszystkich formatów (JSON, Protobuf, Avro).

Data i czas:

Format: ISO 8601 z obowiązkową strefą czasową UTC (2026-04-05T14:28:00.000Z). Strefa inna niż UTC jest zabroniona w API — konwersja odbywa się po stronie klienta.

Precyzja: milisekundy (3 miejsca po sekundach). Mikrosekundy dozwolone w logach i teledetrii.

Typ w JSON Schema: "type": "string", "format": "date-time".

Typ w Protobuf: google.protobuf.Timestamp.

Daty bez czasu (np. data wygaśnięcia certyfikatu): format YYYY-MM-DD (ISO 8601 date).

Czas trwania (duration): ISO 8601 duration (PT1H30M, P7D) lub sekundy jako integer (w Protobuf: google.protobuf.Duration).

Enumy:

JSON: string uppercase z underscore ("ACTIVE", "PENDING_APPROVAL", "TERMINATED"). Nigdy integer.

Protobuf: enum z prefiksem nazwy typu (SESSION_STATUS_ACTIVE, SESSION_STATUS_TERMINATED). Wartość 0 zawsze UNSPECIFIED.

Avro: enum jako named type z pełną listą symboli.

Nowe wartości enum dodawane na końcu. Usunięcie wartości = breaking change.

Konsumenci muszą obsługiwać nieznane wartości enum gracefully (log warning, nie crash).

Pola nullable:

JSON: pole opcjonalne = nie obecne w obiekcie (nie null). Jeśli pole musi być jawnie nullowalne (np. terminatedAt — null dopóki sesja aktywna), stosować "type": ["string", "null"].

Protobuf: opcjonalne pola z optional keyword (proto3). Wrapper types (google.protobuf.StringValue) dla jawnej nullowalności.

Zakaz: puste stringi ("") jako zamiennik null. Pole albo jest obecne z wartością, albo nieobecne.

Identyfikatory:

UUID v4 jako domyślny format identyfikatorów (32 hex + dashes: 550e8400-e29b-41d4-a716-446655440000). Małe litery.

Identyfikatory sekwencyjne (auto-increment) zabronione w API — ujawniają kardynalność i umożliwiają enumerację.

Identyfikatory przyjazne (slug): dozwolone jako alias, ale UUID pozostaje kanonicznym identyfikatorem.

Kwoty i wartości pieniężne:

Kwoty przechowywane jako integer w najmniejszej jednostce waluty (centy): 150000 = 1500,00 EUR.

Waluta jako osobne pole: "currency": "EUR".

Zakaz float/double dla kwot pieniężnych.

53.6 Kontrakty błędów — format, kody, komunikaty, lokalizacja

Status: [N] Normatywny Odbiorca: Backend Developer, Frontend Developer, QA Wpływ na baseline: Wysoki Powiązane rozdziały: 52.3, 53.1, 56.7

Każdy endpoint SYLION musi zwracać błędy w ustandaryzowanym formacie zgodnym z RFC 9457 (Problem Details for HTTP APIs). Format jest obowiązkowy dla wszystkich odpowiedzi z kodem HTTP 4xx i 5xx.

Format odpowiedzi błędu:

```
{ "type": "https://errors.sylion.io/v2/auth/token-expired", "title": "Token expired", "status": 401, "detail": "The provided access token expired at 2026-04-05T14:00:00Z. Please refresh your token.", "instance": "/v2/sessions/abc-123", "traceId": "4bf92f3577b34da6a3ce929d0e0e4736", "timestamp": "2026-04-05T14:28:00.000Z", "errors": [ { "code": "AUTH_TOKEN_EXPIRED", "field": null, "message": "Access token has expired" } ] }
```

Pola obowiązkowe:

type (URI): identyfikator typu błędu, resolwowny do dokumentacji.

title (string): krótki, czytelny tytuł — stały dla danego typu błędu.

status (integer): kod HTTP.

detail (string): szczegółowy opis — może być dynamiczny, ale nie może ujawniać internali systemu (stack traces, nazwy tabel, ścieżki plików).

traceId (string): identyfikator trace (OpenTelemetry) do korelacji z logami.

errors (array): lista szczegółowych błędów (dla walidacji — per-field errors).

Kody błędów:

SYLION definiuje hierarchiczny system kodów błędów: {DOMAIN}_{CATEGORY}_{SPECIFIC}. Przykłady:

AUTH_TOKEN_EXPIRED — token wygasł

AUTH_INSUFFICIENT_SCOPE — brak wymaganego scope

SESSION_NOT_FOUND — sesja nie istnieje

POLICY_VIOLATION_EGRESS — naruszenie polityki egress

OPERATOR_QUOTA_EXCEEDED — przekroczenie limitu operatora

FOUR_EYES_REQUIRED — operacja wymaga dual authorization

Kody są stabilne (nie zmieniają się między wersjami) i dokumentowane w error catalog.

Bezpieczeństwo błędów:

Odpowiedzi błędów nie mogą ujawniać informacji diagnostycznych atakującemu: brak stack traces, brak nazw serwisów wewnętrznych, brak wersji bibliotek.

Błędy 401 i 403 muszą być nierozróżnialne z perspektywy nieautoryzowanego klienta (nie ujawniać, czy zasób istnieje).

Błędy 500 zwracają generyczny komunikat — szczegóły dostępne wyłącznie w logach po traceld.

Lokalizacja:

Pola title i detail są w języku angielskim (domyślnie). Klient może żądać lokalizacji za pomocą nagłówka Accept-Language. Obsługiwane języki: en, pl, de. Lokalizacja jest best-effort — jeśli tłumaczenie nie istnieje, zwracany jest tekst angielski.

53.7 Kontrakty bezpieczeństwa — nagłówki auth, formaty tokenów, zakresy

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 55.1, 55.4, 55.7

Kontrakty bezpieczeństwa definiują standardowy sposób przekazywania informacji uwierzytelniających i autoryzacyjnych w requestach API SYLION.

Nagłówki uwierzytelniające:

Nagłówek	Zastosowanie	Format
Authorization	Token Bearer (OAuth 2.0)	Bearer <JWT>
Client TLS Certificate	mTLS (service-to-service)	X.509 w handshake TLS
X-API-Key	Klucz API (partner integration)	64-znakowy hex string
X-Four-Eyes-Approval	Dual authorization	JWT podpisany przez drugiego admina

Format JWT:

Tokeny JWT w SYLION muszą spełniać:

Algorytm podpisu: ES256 (ECDSA P-256) lub EdDSA (Ed25519). RSA jest dozwolony wyłącznie dla kompatybilności z zewnętrznymi IdP (Azure AD).

Header: {"alg": "ES256", "typ": "JWT", "kid": "<key-id>"}. kid jest obowiązkowy — umożliwia rotację kluczy.

Payload obowiązkowe claims:

iss: issuer — https://auth.sylon.{domain}

sub: subject — identyfikator użytkownika/serwisu

aud: audience — identyfikator docelowego serwisu/API

exp: expiration — max 15 minut dla access tokenów

iat: issued at

jti: JWT ID — unikalny identyfikator tokenu (UUID v4)

scope: lista uprawnień (space-separated)

sylon:operator: identyfikator operatora

sylon:zone: strefa, z której token został wydany

sylon:tier: tier operatora (STANDARD/PRO/STATE)

Zakresy (Scopes):

System zakresów w SYLION jest hierarchiczny: {resource}:{action}.

sessions:read — odczyt sesji

sessions:write — tworzenie/modyfikacja sesji

sessions:terminate — terminacja sesji

operators:admin — zarządzanie operatorami

policies:write — modyfikacja polityk

audit:read — odczyt logów audytowych

audit:export — eksport dowodów audytowych

secrets:rotate — rotacja tajemnic (wymaga Four-Eyes)

management:destructive — operacje destrukcyjne (wymaga Four-Eyes)

Scope * (wildcard) jest zabroniony. Least privilege: każdy token musi zawierać minimalny zestaw zakresów wymagany do wykonania operacji.

Token refresh:

Refresh tokeny: czas życia max 24h (STANDARD), 8h (PRO), 4h (STATE). Jednorazowe użycie (one-time use) — po wymianie stary refresh token jest unieważniany. Refresh tokeny przechowywane w HttpOnly, Secure, SameSite=Strict cookie (dla klientów przeglądarkowych) lub w bezpiecznym storage urządzenia.

53.8 Testy kontraktowe — consumer-driven contracts (Pact), wykrywanie breaking changes

Status: [N] Normatywny Odbiorca: Backend Developer, QA, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 53.1, 53.2, 54.7

Testy kontraktowe stanowią obowiązkowy element pipeline'u CI/CD w SYLION, zapewniając że zmiany w API nie powodują nieoczekiwanych awarii konsumentów. SYLION wymaga podejścia Consumer-Driven Contracts (CDC).

Framework:

Pact (lub kompatybilny — np. Spring Cloud Contract) jest obowiązkowym narzędziem do testów kontraktowych. Pact Broker jest deployowany w Zone 4 jako shared service.

Workflow CDC:

Konsument definiuje kontrakt: zespół konsumencki (np. frontend, SDK, adapter) definiuje oczekiwane interakcje z API (request → expected response). Kontrakt jest generowany przez testy jednostkowe konsumenta.

Kontrakt publikowany do Pact Broker: pact-broker publish.

Provider weryfikuje kontrakt: pipeline CI dostawcy (mikroserwisu) uruchamia weryfikację: czy implementacja spełnia kontrakty wszystkich konsumentów.

Can-I-Deploy: przed deploymentem, pact-broker can-i-deploy weryfikuje, czy wersja dostawcy jest kompatybilna ze wszystkimi zdeployowanymi konsumentami (i odwrotnie).

Scope testów kontraktowych:

Testy kontraktowe weryfikują: - Statusy HTTP (konsument oczekuje 200, dostawca zwraca 200). - Strukturę body (pola, typy, zagnieżdżenie — ale nie konkretne wartości). - Nagłówki (Content-Type, Cache-Control, security headers). - Kody błędów (konsument obsługuje specyficzne kody błędów).

Testy kontraktowe nie zastępują testów integracyjnych — weryfikują kontrakt, nie logikę biznesową.

Wykrywanie breaking changes:

Oprócz Pact, SYLION wymaga automatycznego wykrywania breaking changes na poziomie specyfikacji:

OpenAPI diff: narzędzie oasdiff porównuje aktualną specyfikację z wersją produkcyjną. Breaking changes: usunięcie endpointu, zmiana typu parametru, usunięcie pola z response, dodanie wymaganego pola do request.

Protobuf diff: buf breaking porównuje pliki .proto.

Avro compatibility check: Schema Registry wymusza kompatybilność przy rejestracji nowej wersji.

Blokada deployment:

Breaking change wykryty w CI → pipeline FAIL → merge zablokowany. Jedynym sposobem na wprowadzenie breaking change jest stworzenie nowej major version API (patrz 54.1) z zachowaniem starej wersji przez minimum 6 miesięcy.

Matryca odpowiedzialności:

Artefakt	Twórca kontraktu	Weryfikator
REST API	Konsument (Pact)	Dostawca (Provider verification)
gRPC	Protobuf schema owner	buf breaking w CI
Events	Schema owner	Schema Registry compatibility
Webhooks	SYLION (dostawca)	Partner (consumer tests)

Rozdział 54. Wersjonowanie API i kompatybilność

54.1 Zasady wersjonowania — URI versioning, header versioning

Status: [N] Normatywny Odbiorca: Architekt, Backend Developer, Product Owner Wpływ na baseline: Krytyczny Powiązane rozdziały: 52.3, 53.2, 54.2

SYLION stosuje URI versioning jako obowiązkowy mechanizm wersjonowania API REST. Wersja jest częścią ścieżki URL w formacie /v{major}/ (np. /v2/operators). Ta decyzja wynika z priorytetów: jednoznaczność, cacheability, czytelność logów i łatwość routingu na API Gateway.

URI versioning — reguły:

Tylko major version w URL: /v2/, /v3/. Minor i patch versions nie są częścią URL.

Major version bump wyłącznie przy breaking changes (patrz 54.2 — taksonomia).

Aktualnie obowiązująca wersja: v2. Poprzednia (v1) — deprecated, sunset za 12 miesięcy.

Bazowy URL: https://api.sylon.{domain}/v2/.

Header versioning — rola uzupełniająca:

Nagłówek Accept-Version służy do negocjacji minor version w obrębie major version. Przykład: Accept-Version: 2.3. Jeśli klient nie podaje nagłówka — serwer zwraca najnowszą minor version w ramach żądanej major version. Header versioning nie jest stosowany do breaking changes — te wymagają nowej major version

w URL.

API Gateway routing:

API Gateway (Zone 1) routuje requesty na podstawie prefiksu URL (/v2/ → backend v2, /v3/ → backend v3). Obie wersje mogą współistnieć w produkcji przez okres sunset. Gateway dodaje nagłówek X-API-Version: 2.3.1 do każdej odpowiedzi, informując klienta o dokładnej wersji serwisu.

gRPC versioning:

Dla gRPC wersja jest częścią pakietu proto: package sylion.session.v2;. Nowa major version = nowy pakiet. Serwis gRPC może obsługiwać wiele wersji jednocześnie (multiple service implementations). Client discovery za pomocą service mesh — klient żąda konkretnej wersji serwisu.

Dokumentacja wersji:

Developer portal publikuje dokumentację dla każdej aktywnej wersji. Wersje deprecated są oznaczone wizualnie i zawierają link do migration guide.

54.2 Breaking vs non-breaking changes — taksonomia

Status: [N] Normatywny Odbiorca: Backend Developer, Architekt, QA Wpływ na baseline: Krytyczny Powiązane rozdziały: 54.1, 53.8, 54.5

Precyzyjna klasyfikacja zmian API jako breaking lub non-breaking jest fundamentem strategii wersjonowania. SYLION definiuje następującą taksonomię:

Breaking changes (wymagają nowej major version):

Usunięcie endpointu.

Zmiana metody HTTP endpointu (np. POST → PUT).

Usunięcie pola z response body.

Zmiana typu pola (np. string → integer).

Dodanie wymaganego pola do request body.

Zmiana semantyki istniejącego pola (np. pole status zmienia zbiór dozwolonych wartości).

Zawężenie wartości enum (usunięcie wartości).

Zmiana kodów błędów dla istniejących scenariuszy.

Zmiana formatu identyfikatorów (np. integer → UUID).

Zmiana mechanizmu uwierzytelniania endpointu.

Zmiana semantyki kodu HTTP (np. 200 → 201).

Non-breaking changes (minor version bump):

Dodanie nowego endpointu.

Dodanie opcjonalnego pola do request body.

Dodanie pola do response body.

Rozszerzenie enum o nową wartość (przy zachowaniu istniejących).

Dodanie nowego parametru query string (opcjonalnego).

Dodanie nowego nagłówka response.

Zmiana opisu/dokumentacji bez zmiany zachowania.

Poprawa wydajności bez zmiany kontraktu.

Dodanie nowego kodu błędu (nowy scenariusz).

Szara strefa — wymaga analizy:

Zmiana domyślnej wartości paginacji — non-breaking, ale wymaga komunikacji.

Dodanie walidacji (np. nowe ograniczenie długości pola) — breaking dla klientów wysyłających dane przekraczające limit.

Zmiana kolejności pól w response — non-breaking (JSON jest unordered), ale może łamać źle napisanych klientów.

Każda zmiana z „szarej strefy” wymaga decyzji ARB z dokumentacją.

54.3 Negocjacja wersji

Status: [N] Normatywny Odbiorca: Backend Developer, Architekt Wpływ na baseline: Średni Powiązane rozdziały: 54.1, 54.4

Mechanizm negocjacji wersji w SYLION jest dwuwarstwowy:

Warstwa 1 — Major version (URI):

Klient wskazuje major version w URL. Jeśli żądana wersja nie istnieje — HTTP 404 z type: https://errors.sylion.io/v2/api/version-not-found. Jeśli wersja jest deprecated — odpowiedź zawiera nagłówek Deprecation: true oraz Sunset: <date>.

Warstwa 2 — Minor version (Header):

Nagłówek Accept-Version: 2.3 żąda konkretnej minor version. Reguły: - Jeśli żądana minor version istnieje → serwer odpowiada tą wersją. - Jeśli żądana minor version nie istnieje, ale jest niższa niż najnowsza → serwer odpowiada najnowszą (backward-compatible). - Jeśli żądana minor version jest wyższa niż najnowsza → HTTP 406 Not Acceptable. - Jeśli nagłówek pominięty → najnowsza minor version.

Odpowiedzi:

Każda odpowiedź zawiera nagłówki: - X-API-Version: 2.3.1 — faktyczna wersja serwisu. - Deprecation: true / brak — czy wersja jest deprecated. - Sunset: Sat, 01 Oct 2027 00:00:00 GMT — data wygaśnięcia (jeśli deprecated). - Link: <https://docs.sylon.io/migration/v2-to-v3>; rel="successor-version" — link do migration guide.

54.4 Polityka sunset i deprecation — minimum 6 miesięcy

Status: [N] Normatywny Odbiorca: Product Owner, Architekt, Partner Integration, Customer Success Wpływ na baseline: Krytyczny Powiązane rozdziały: 54.1, 54.3, 59.9

Deprecated API version musi pozostać aktywna przez minimum 6 miesięcy od daty ogłoszenia deprecation. Dla klientów STATE tier — minimum 12 miesięcy (gwarancja kontraktowa).

Procedura sunset:

T-0 (ogłoszenie): Nowa major version jest dostępna w produkcji. Stara wersja oznaczona jako deprecated. Komunikacja: email do wszystkich zarejestrowanych partnerów, banner w developer portalu, changelog entry.

T+30 dni: Metryki użycia starej wersji — jeśli > 10% ruchu → komunikacja follow-up.

T+90 dni: Degradacja QoS starej wersji (niższe rate limity — 50% dotychczasowych). Dodatkowa komunikacja.

T+150 dni (T-30 przed sunset): Ostatnie ostrzeżenie. Response header Warning: 299 - "API v2 will be removed on 2027-10-01".

T+180 dni (sunset): Stara wersja zwraca HTTP 410 Gone dla wszystkich requestów. Body zawiera migration guide URL.

Wyjątki:

Tier STATE: sunset nie może nastąpić wcześniej niż 12 miesięcy od ogłoszenia, chyba że zmiana jest wymagana przez krytyczną podatność bezpieczeństwa.

Security-critical deprecation (np. odkrycie podatności w starej wersji): fast-track sunset — 30 dni z powiadomieniem. Stara wersja może być wyłączona szybciej za zgodą CISO.

Monitoring sunset:

Dashboard monitorujący ruch na deprecated endpointach — widoczny dla Product Owner i Partner Integration Team. Alerty przy >5% ruchu na deprecated endpoints w ostatnim miesiącu przed sunset.

54.5 Wymagania kompatybilności wstecznej

Status: [N] Normatywny Odbiorca: Backend Developer, Architekt, QA Wpływ na baseline: Krytyczny Powiązane rozdziały: 54.2, 53.8, 57.6

Kompatybilność wsteczna (backward compatibility) jest wymagana w obrębie major version. Klient napisany dla v2.0 musi działać z v2.x bez modyfikacji.

Reguły:

Pola dodane do response nie mogą łamać deserializacji klientów (klienci muszą ignorować nieznane pola — reguła „be liberal in what you accept”).

Nowe opcjonalne parametry request nie mogą zmieniać domyślnego zachowania endpointu.

Kody błędów dodane w nowej minor version nie mogą zastępować istniejących kodów.

Domyślne wartości paginacji, sortowania i filtrów nie mogą się zmieniać w obrębie major version.

Semantyka istniejących pól jest niezmienna — nawet jeśli nazwa sugeruje szersze znaczenie.

Testy:

Suite testów regresyjnych utrzymywany jest dla każdej major version. Suite zawiera „frozen” testy — snapshoty requestów/responsów z dnia release’u major version. Te testy muszą przechodzić przez cały cykl życia major version. Każdy PR jest weryfikowany przeciw frozen suite.

54.6 Kompatybilność kontraktów danych

Status: [N] Normatywny Odbiorca: Backend Developer, Data Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 53.1, 53.3, 57.6

Kompatybilność kontraktów danych rozciąga się poza API — obejmuje schematy baz danych, formaty zdarzeń w brokerze i formaty artefaktów.

Macierz kompatybilności:

Artefakt	Wymagana kompatybilność	Narzędzie weryfikacji
REST API response	Backward	oasdiff, Pact
REST API request	Forward (dodaj opcjonalne)	oasdiff, Pact
gRPC messages	Backward	buf breaking
Event schemas	Full (backward + forward)	Schema Registry
Database schema	Forward-compatible migrations	Flyway + custom gates
Audit log format	Full (nigdy nie łamać)	Custom frozen tests

Ewolucja danych:

Zmiany schematu bazy danych muszą być forward-compatible: nowa wersja schematu musi działać ze starą wersją kodu (na wypadek rollback). Oznacza to:

Dodanie kolumny: z wartością domyślną (nie NULL constraint od razu).

Usunięcie kolumny: dwufazowe — najpierw kod przestaje używać, potem migracja usuwa.

Zmiana typu kolumny: nowa kolumna + migracja danych + stary kod czyta obie + usunięcie starej.

Szczegóły procedury migracji — patrz 57.6.

54.7 Testy regresji API

Status: [N] Normatywny Odbiorca: QA, Backend Developer, DevSecOps Wpływ na baseline: Wysoki Powiązane rozdziały: 53.8, 54.5, 70.2

Testy regresji API stanowią ostatnią linię obrony przed niezamierzonymi breaking changes. SYLION wymaga trzech warstw:

Warstwa 1 — Contract tests (Pact):

Opisane w 53.8. Uruchamiane w CI przy każdym PR. Czas wykonania: <2 min.

Warstwa 2 — Frozen snapshot tests:

Snapshots request/response dla każdego endpointu, zebrane w dniu release'u major version. Przechowywane w repozytorium api-regression-snapshots.

Porównanie structuralne (nie wartości, ale typy i obecność pól). Uruchamiane w CI przy każdym PR.

Warstwa 3 — End-to-end API tests:

Pełne scenariusze użycia (np. „utwórz operatora → utwórz environment → utwórz sesję → terminuj sesję”). Uruchamiane na staging environment przed promocją do produkcji. Czas wykonania: <15 min. Testy E2E muszą pokrywać:

Happy path dla każdego głównego flow.

Scenariusze błędów (brak autoryzacji, brak zasobu, conflict).

Scenariusze Four-Eyes (operacje wymagające dual authorization).

Paginację i filtrowanie.

Rate limiting (weryfikacja HTTP 429).

Metryki:

Coverage: 100% endpointów musi mieć min. 1 test contract + 1 frozen snapshot.

Pass rate: 100% wymagane dla merge/deploy. Żaden test nie może być @Ignored bez zatwierdzenia ARB.

Flakiness: testy z >2% flakiness są oznaczane i muszą być naprawione w ciągu 5 dni roboczych.

Rozdział 55. Autoryzacja i uwierzytelnianie API

55.1 OAuth 2.0 — Authorization Code + PKCE dla interaktywnych, Client Credentials dla service-to-service

Status: [N] Normatywny Odbiorca: Backend Developer, Security Architect, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 53.7, 55.2, 55.4

OAuth 2.0 (RFC 6749, RFC 7636) stanowi obowiązkowy framework autoryzacji dla SYLION API. Dwa grant types są dozwolone — wybór zależy od typu klienta.

Authorization Code + PKCE (interaktywni użytkownicy):

Stosowany dla: panelu administratora, developer portalu, dashboardu operatorskiego, aplikacji mobilnych, thin clientów. PKCE (Proof Key for Code Exchange) jest obowiązkowy dla wszystkich klientów — w tym confidential clients (dodatkowa warstwa ochrony).

Flow: 1. Klient generuje code_verifier (128 bajtów losowych, base64url) i code_challenge = SHA-256(code_verifier). 2. Redirect do authorization endpointu: GET /oauth2/authorize?response_type=code&client_id=...&redirect_uri=...&scope=...&code_challenge=...&code_challenge_method=S256&state=.... 3. Użytkownik uwierzytelnia się (FIDO2/WebAuthn jako primary, hasło + TOTP jako fallback). 4. Authorization server zwraca code na redirect_uri. 5. Klient wymienia code na tokeny: POST /oauth2/token z code, code_verifier, client_id, redirect_uri. 6. Serwer zwraca: access_token (JWT, TTL 15min), refresh_token (opaque, TTL per-tier), id_token (OIDC).

Client Credentials (service-to-service):

Stosowany dla: komunikacji między mikroserwisami, adapterów integracyjnych, automatyzacji CI/CD, scheduled jobs. Klient uwierzytelnia się za pomocą client_id + client_secret (lub mTLS — preferowane) i otrzymuje access_token bez udziału użytkownika.

Ograniczenia Client Credentials: - Token nie zawiera kontekstu użytkownika (sub = service identity, nie user). - Scope ograniczony do uprawnień serwisu (least privilege). - client_secret przechowywany w Vault — nigdy w kodzie, configmapach, zmiennych środowiskowych. - Rotacja client_secret co 90 dni (automatyczna przez Vault).

Zabronione grant types:

Implicit Grant — zabroniony (podatny na token leakage).

Resource Owner Password Credentials (ROPC) — zabroniony (wymaga przesyłania haseł do aplikacji).

Device Authorization Grant — dozwolony wyłącznie za zgodą Security Team dla specyficznych urządzeń IoT.

55.2 OpenID Connect (OIDC)

Status: [N] Normatywny Odbiorca: Backend Developer, Security Architect, Identity Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 55.1, 55.4, 59.1

OIDC (warstwa tożsamości na OAuth 2.0) jest obowiązkowym protokołem uwierzytelniania użytkowników w SYLION. Authorization Server SYLION jest jednocześnie OIDC Provider (OP).

Wymagane endpointy OIDC:

/well-known/openid-configuration — discovery document.

/oauth2/authorize — authorization endpoint (z PKCE).

/oauth2/token — token endpoint.

/oauth2/userinfo — user info endpoint (zwraca claims).

/oauth2/jwks — JSON Web Key Set (klucze publiczne do weryfikacji JWT).

/oauth2/revoke — token revocation (RFC 7009).

/oauth2/introspect — token introspection (RFC 7662) — wyłącznie dla serwisów wewnętrznych.

ID Token claims:

```
{ "iss": "https://auth.sylion.example.com", "sub": "user-uuid-123", "aud": "sylion-admin-portal", "exp": 1712345678, "iat": 1712344778, "auth_time": 1712344700, "nonce": "random-nonce", "acr": "urn:sylion:acr:fido2", "amr": ["fido2"], "sylion:operator": "op-456", "sylion:roles": ["operator-admin", "soc-viewer"], "sylion:tier": "STATE" }
```

ACR (Authentication Context Class Reference):

SYLION definiuje poziomy uwierzytelniania: - urn:sylion:acr:password — hasło + TOTP (minimum dla STANDARD). - urn:sylion:acr:fido2 — FIDO2/WebAuthn (minimum dla PRO i STATE). - urn:sylion:acr:fido2+pin — FIDO2 + PIN urządzenia (wymagany dla operacji destrukcyjnych).

Operacje o wysokim ryzyku (Four-Eyes, usunięcie operatora, rotacja root CA) wymagają acr: fido2+pin i step-up authentication — nawet jeśli użytkownik jest zalogowany z niższym ACR.

Federacja:

SYLION OP może federować tożsamości z zewnętrznymi IdP (Azure AD, Okta, LDAP/AD) za pomocą OIDC Federation lub SAML 2.0 bridge. Zewnętrzne tożsamości są mapowane na wewnętrzne role SYLION w module Identity Mapping (patrz 59.1). Federacja nie zmienia wymagań ACR — external IdP musi potwierdzić ACR odpowiedni do żądanej operacji.

55.3 mTLS dla service-to-service

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 55.1, 55.9, 65.2

Mutual TLS (mTLS) jest obowiązkowym mechanizmem uwierzytelniania dla komunikacji service-to-service w SYLION. Każdy mikroserwis posiada certyfikat X.509 identyfikujący go w sieci.

Wymagania certyfikatów:

Wydawca: wewnętrzny PKI zarządzany przez HashiCorp Vault (Vault PKI Secrets Engine).

Hierarchia: Root CA (offline, HSM-backed) → Intermediate CA per-zone → Service certificates.

Algorytm: ECDSA P-256 (domyślnie) lub Ed25519. RSA-2048 dozwolony wyłącznie dla legacy integracji.

TTL certyfikatu serwisowego: max 72 godziny. Automatyczna rotacja przed wygaśnięciem (renew at 2/3 TTL).

SAN (Subject Alternative Name): musi zawierać SPIFFE ID serwisu (patrz 55.9).

Extended Key Usage: serverAuth + clientAuth.

Egzekwowanie mTLS:

Service mesh (Envoy-based sidecar proxy) terminuje mTLS i weryfikuje certyfikat peera. Konfiguracja: - STRICT mode: wyłącznie mTLS (brak fallback na plaintext). Obowiązkowy w Zone 3, Zone 4, Zone 5. - PERMISSIVE mode: mTLS preferowany, plaintext dozwolony. Wyłącznie podczas migracji (max 7 dni).

Autoryzacja na podstawie tożsamości certyfikatu:

Po weryfikacji certyfikatu, sidecar proxy wyodrębnia SPIFFE ID i porównuje z polityką autoryzacji (OPA). Przykład polityki:

```
allow { input.source.principal == "spiffe://sylion.local/zone3/policy-engine" input.destination.principal == "spiffe://sylion.local/zone3/session-broker"
input.request.method == "POST" }
```

Certificate pinning:

Certificate pinning jest stosowany na poziomie serwisu (pin intermediate CA, nie leaf cert) aby uniemożliwić akceptację certyfikatów wydanych przez inną CA w przypadku kompromitacji root CA. Pinning aktualizowany automatycznie przy rotacji intermediate CA.

55.4 JWT — podpisywanie, walidacja, wygasanie, audience

Status: [N] Normatywny Odbiorca: Backend Developer, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 53.7, 55.1, 55.5

Podpisywanie:

Tokeny JWT są podpisywane przez Authorization Server. Klucze podpisu: - Algorytm: ES256 (ECDSA P-256) — domyślny. EdDSA (Ed25519) — dozwolony. RS256 — wyłącznie dla kompatybilności z zewnętrznymi IdP. - Klucze prywatne przechowywane w HSM (FIPS 140-3 Level 3) lub Vault Transit Engine. - Rotacja kluczy podpisu: co 30 dni. JWKS endpoint (/oauth2/jwks) publikuje aktualny i poprzedni klucz (overlap 48h). - kid (Key ID) obowiązkowy w headerze JWT — identyfikuje klucz podpisu.

Walidacja:

Każdy serwis weryfikujący JWT musi: 1. Pobrać JWKS z Authorization Server (cache: 5 min TTL, background refresh). 2. Zweryfikować podpis za pomocą klucza identyfikowanego przez kid. 3. Zweryfikować iss — musi odpowiadać skonfigurowanemu issuerowi. 4. Zweryfikować aud — musi zawierać identyfikator weryfikującego serwisu. 5. Zweryfikować exp — z tolerancją clock skew max 30 sekund. 6. Zweryfikować iat — nie może być z przyszłości (z tolerancją 30s). 7. Opcjonalnie: sprawdzić jti w cache (ochrona przed replay — wymagana dla operacji mutujących).

Wygasanie:

Typ tokenu	TTL	Odnawianie
Access token	15 minut	Przez refresh token
ID token	15 minut	Przez re-authentication
Refresh token (STANDARD)	24 godziny	Jednorazowy (rotation)
Refresh token (PRO)	8 godzin	Jednorazowy (rotation)
Refresh token (STATE)	4 godziny	Jednorazowy (rotation)
Service token (Client Credentials)	60 minut	Nowy grant

Audience (aud):

Claim aud jest obowiązkowy i musi precyzyjnie identyfikować docelowy serwis/API. Format: `https://api.sylion.{domain}/v2/{service}`. Token z aud przeznaczonym dla session-broker nie będzie zaakceptowany przez policy-engine. Audience validation jest obowiązkowa — brak walidacji aud stanowi defekt bezpieczeństwa P0.

Token binding:

Dla operacji wysokiego ryzyka, SYLION rekomenduje DPoP (Demonstrating Proof-of-Possession, RFC 9449) — token jest powiązany z kluczem kryptograficznym klienta. DPoP jest obowiązkowy dla tier STATE.

55.5 Token exchange

Status: [N] Normatywny Odbiorca: Backend Developer, Security Architect Wpływ na baseline: Wysoki Powiązane rozdziały: 55.4, 55.6, 55.9

Token exchange (RFC 8693) umożliwia serwisowi wymianę tokenu na inny token z innymi uprawnieniami lub audience — kluczowy mechanizm dla komunikacji cross-service w Zero Trust.

Scenariusze:

Delegation: Serwis A działa w imieniu użytkownika i potrzebuje wywołać serwis B. Serwis A wymienia token użytkownika na nowy token z aud serwisu B i ograniczonym scope (least privilege).

Impersonation: Zabroniona domyślnie. Dozwolona wyłącznie dla SOC w trybie incident response z logowaniem Four-Eyes.

Service-to-service elevation: Serwis potrzebuje dodatkowego scope (np. emergency revocation). Token exchange z dodatkowym claim act identyfikującym acting party.

Endpoint: `POST /oauth2/token` z `grant_type=urn:ietf:params:oauth:grant-type:token-exchange`.

Parametry: - `subject_token`: oryginalny token (JWT). - `subject_token_type`: `urn:ietf:params:oauth:token-type:access_token`. - `audience`: docelowy serwis. - `scope`: żądane zakresy (muszą być podzbiorem oryginalnych + dozwolone przez politykę). - `requested_token_type`: `urn:ietf:params:oauth:token-type:access_token`.

Bezpieczeństwo:

Token exchange jest logowany w audit log (kto, kiedy, z jakiego tokenu na jaki, jaki scope).

łańcuch delegacji jest ograniczony do 3 kroków ($A \rightarrow B \rightarrow C \rightarrow D$). Dalsze delegacje są blokowane.

Token wymieniony ma krótszy TTL niż oryginalny (max 5 minut).

Policy engine (OPA) weryfikuje, czy exchange jest dozwolony na podstawie polityk per-serwis.

55.6 Audience scoping

Status: [N] Normatywny Odbiorca: Backend Developer, Security Architect Wpływ na baseline: Wysoki Powiązane rozdziały: 55.4, 55.5, 55.7

Audience scoping zapewnia, że tokeny są akceptowane wyłącznie przez docelowe serwisy, ograniczając blast radius w przypadku wycieku tokenu.

Zasady:

Każdy token musi mieć jawny aud claim identyfikujący docelowy serwis lub grupę serwisów.

Serwis weryfikujący token musi odrzucić tokeny z aud nie zawierającym jego identyfikatora.

Multi-audience tokeny (lista w aud) są dozwolone wyłącznie gdy serwisy są w tej samej strefie i domenie.

Tokeny bez aud są odrzucane — brak audience = defekt bezpieczeństwa.

Identyfikatory audience:

Format: URI — `https://api.sylion.{domain}/v2/{service-name}`. Przykłady: - `https://api.sylion.example/v2/session-broker` - `https://api.sylion.example/v2/policy-engine` - `https://api.sylion.example/v2/audit-service`

Dla grup serwisów (np. wszystkie serwisy Zone 3): `https://api.sylion.example/zone3` — dozwolone wyłącznie dla service mesh internal communication z dodatkowym mTLS.

Egzekwowanie:

API Gateway (Zone 1) weryfikuje aud dla requestów z zewnątrz. Service mesh sidecar weryfikuje aud dla requestów wewnętrznych. Podwójna weryfikacja (gateway + sidecar) dla requestów cross-zone.

55.7 Fine-grained authorization — integracja z OPA

Status: [N] Normatywny Odbiorca: Backend Developer, Security Architect, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 55.1, 55.6, 62.2

Open Policy Agent (OPA) stanowi obowiązkowy silnik autoryzacji fine-grained w SYLION. OPA jest deployowany jako sidecar do każdego mikroservisu (Zone 3, 4, 5) oraz jako centralny policy decision point w Zone 4.

Architektura:

[Request] → [Envoy Sidecar] → [OPA Sidecar] → [Decision: allow/deny] ↓ [Policy Bundle] (pobierany z OPA Bundle Server)

Model polityk:

Polityki napisane w języku Rego, organizowane w pakiety per-serwis i per-domena:

```
package sylion.session_broker.authz import future.keywords.in default allow := false # Operator może czytać sesje w swoim scope allow { input.method == "GET"
input.path[0] == "v2" input.path[1] == "sessions" input.token.sylion_operator == input.resource.operator_id "sessions:read" in input.token.scope } # Terminacja sesji
wymaga scope + operator match allow { input.method == "POST" input.path[3] == "terminate" input.token.sylion_operator == input.resource.operator_id
"sessions:terminate" in input.token.scope } # Operacje destrukcyjne wymagają Four-Eyes allow { input.method == "DELETE" "management:destructive" in
input.token.scope input.four_eyes_approval.valid == true input.four_eyes_approval.approver != input.token.sub }
```

Data-driven policies:

OPA umożliwia policies oparte na danych zewnętrznych (np. lista aktywnych operatorów, macierz ról, konfiguracja tierów). Dane dostarczane przez OPA Bundle Server, aktualizowane co 30 sekund. Dane wrażliwe (np. lista suspendowanych operatorów) nie są wbudowane w politykę — pobierane dynamicznie.

Logowanie decyzji:

Każda decyzja autoryzacyjna (allow/deny) jest logowana z kontekstem: token claims, resource, action, decision, policy path, evaluation time. Logi decyzji trafiają do centralnego audit log. Decyzje deny generują alert dla SOC przy przekroczeniu progu (>10 deny/min z jednego IP/tokenu).

Testowanie polityk:

Polityki Rego muszą posiadać testy jednostkowe (OPA test framework) z coverage >90%. Testy uruchamiane w CI przy każdym PR. Polityki bez testów nie mogą być wdrożone.

55.8 Klucze API — ograniczone, wyłącznie dla integracji partnerskich

Status: [R] Rekomendowany Odbiorca: Partner Integration, Backend Developer, Security Architect Wpływ na baseline: Średni Powiązane rozdziały: 55.1, 55.7, 59.9

Klucze API stanowią uproszczony mechanizm uwierzytelniania, dozwolony wyłącznie dla integracji partnerskich (certified integrators) w ściśle ograniczonym zakresie.

Kiedy klucz API:

Partner zewnętrzny integruje się z SYLION API dla read-only operations (odczyt statusu operatora, eksport metryk, odczyt konfiguracji).

Scenariusze server-to-server, gdzie OAuth Client Credentials jest niewykonalny (np. legacy system partnera).

Nigdy dla operacji mutujących (create, update, delete). Nigdy dla dostępu do danych wrażliwych (audit logs, secrets, sessions).

Format i generowanie:

Format: sylk_ + 58 znaków base62 (np. sylk_aB3cD4eF5gH6iJ7kL8mN9oP0qR1sT2uV3wX4yZ5aB3cD4eF5gH6).

Generowanie: kryptograficznie losowe (CSPRNG), 256 bitów entropii.

Przechowywanie: hash (SHA-256) w bazie danych. Klucz wyświetlany jednorazowo przy generowaniu.

Per-partner: max 3 aktywne klucze jednocześnie.

TTL: max 365 dni. Brak auto-renewal — partner musi wygenerować nowy klucz.

Ograniczenia:

IP allowlist: klucz API jest powiązany z listą dozwolonych adresów IP partnera (max 10 IP/CIDR).

Rate limit: 100 req/min per klucz (niezależnie od globalnego rate limitu).

Scope: jawnie zdefiniowany przy generowaniu. Nie może być rozszerzony bez nowego klucza.

Brak dostępu do endpointów: /operators/*/sessions, /audit-logs, /secrets/*, /certificates/*.

Monitoring:

Użycie kluczy API jest logowane i monitorowane. Anomalie (nagły wzrost ruchu, requesty z nowego IP, próby dostępu do niedozwolonych endpointów) generują alert. Klucz może być natychmiast unieważniony przez SOC.

55.9 Tożsamości serwisów — SPIFFE/SVID

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect, Backend Developer Wpływ na baseline: Krytyczny Powiązane rozdziały: 55.3, 55.7, 65.2

SPIFFE (Secure Production Identity Framework for Everyone) stanowi obowiązkowy standard tożsamości serwisów w SYLION. Każdy mikroservis, workload i komponent infrastruktury posiada tożsamość SPIFFE wyrażoną jako SVID (SPIFFE Verifiable Identity Document).

SPIFFE ID — format:

spiffe://syllion.{deployment-domain}/{zone}/{service-name}

Przykłady: - spiffe://syllion.local/zone3/session-broker - spiffe://syllion.local/zone3/policy-engine - spiffe://syllion.local/zone4/vault-agent -

spiffe://syllion.local/zone5/orchestrator

SVID — realizacja:

SVID w SYLION jest realizowany jako certyfikat X.509 z SPIFFE ID w SAN (Subject Alternative Name) — zgodnie ze specyfikacją X509-SVID. Certyfikat wydawany przez SPIRE Server (SPIFFE Runtime Environment) zintegrowany z Vault PKI.

SPIRE deployment:

SPIRE Server: deployowany w Zone 5 (management), HA (minimum 2 repliki).

SPIRE Agent: deployowany jako DaemonSet na każdym nodzie. Agent komunikuje się z Server przez mTLS.

Workload attestation: SPIRE Agent weryfikuje tożsamość workloadu na podstawie attestora (Kubernetes PSAT, Docker, bare metal — zależnie od środowiska).

Node attestation: Agent weryfikuje tożsamość noda (AWS IID, Azure MSI, TPM-based).

Polityki rejestracji:

Każdy workload musi być jawnie zarejestrowany w SPIRE Server z przypisanym SPIFFE ID. Automatyczna rejestracja (auto-registration) jest dozwolona wyłącznie w Zone 3 dla workloadów provisionowanych przez orchestrator (z weryfikacją attestora). Rejestracja manualna wymagana dla Zone 5 (management plane).

Rotacja:

SVID (certyfikat) ma TTL 1 godzina. Automatyczna rotacja przez SPIRE Agent (renew at 50% TTL). Rotacja jest transparentna dla workloadu — SPIRE Agent dostarcza nowy certyfikat do Envoy sidecar za pomocą SDS (Secret Discovery Service) API.

Trust domain:

Każdy deployment SYLION operuje w osobnej trust domain (syllion.{deployment-domain}). Federacja między trust domains (np. multi-region deployment) wymaga jawnej konfiguracji trust bundle exchange w SPIRE.

Rozdział 56. QoS, throttling i SLA dla endpointów

56.1 Rate limiting — per-klient, per-endpoint, per-tenant

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 52.7, 56.2, 56.5

Rate limiting stanowi obowiązkowy mechanizm ochrony API SYLION przed przeciążeniem, nadużyciem i atakami typu denial-of-service. System stosuje wielowarstwowy rate limiting egzekwowany na API Gateway (Zone 1) i potwierdzany na poziomie mikroserwisu.

Per-klient (per-identity):

Każdy uwierzytelniony klient (użytkownik, serwis, klucz API) posiada indywidualny limit requestów. Limity domyślne:

Tier	Limit per-klient	Burst
STANDARD	200 req/min	50 req/s (burst window 5s)
PRO	500 req/min	100 req/s
STATE	1000 req/min	200 req/s
Partner (API Key)	100 req/min	20 req/s
Service-to-service (internal)	5000 req/min	500 req/s

Limity konfigurowane per-deployment — powyższe są domyślne. Zmiana wymaga zatwierdzenia ARB.

Per-endpoint:

Endpointy krytyczne posiadają dedykowane limity niezależne od limitu per-klient:

POST /oauth2/token: 30 req/min per IP (ochrona przed brute force).

POST /v2/sessions: 50 req/min per operator (ochrona przed session flood).

DELETE /v2/operators/*: 5 req/h per admin (operacje destrukcyjne).

GET /v2/audit-logs: 60 req/min per klient (ochrona przed exfiltracją).

Per-tenant (per-operator):

Limity agregowane na poziomie operatora — suma requestów wszystkich użytkowników i serwisów operatora nie może przekroczyć:

Tier	Limit per-operator
STANDARD	5 000 req/min
PRO	20 000 req/min
STATE	100 000 req/min

Implementacja:

Algorytm: sliding window log (Redis-based). Token bucket jako alternatywa dla endpointów o niskim wolumenie. Rate limiter deployowany na API Gateway z Redis cluster jako backend (Zone 1). Failopen policy: jeśli Redis jest niedostępny, rate limiter przechodzi w tryb passthrough z logowaniem — nie blokuje ruchu (availability over security dla warstwy rate limiting — bezpieczeństwo zapewnione przez inne kontrole).

Nagłówki odpowiedzi:

X-RateLimit-Limit: 200 X-RateLimit-Remaining: 150 X-RateLimit-Reset: 1712345678 Retry-After: 30

Przy przekroczeniu limitu: HTTP 429 Too Many Requests z Retry-After header.

56.2 Kontrola burst

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps Wpływ na baseline: Wysoki Powiązane rozdziały: 56.1, 56.7, 56.8

Burst control chroni backend przed nagłymi spikami ruchu, które mogą wystąpić nawet w ramach ogólnego limitu rate.

Token Bucket:

Dla endpointów o dużym wolumenie stosowany jest algorytm token bucket z dwoma parametrami: - rate: tokeny dodawane per sekunda. - burst: maksymalna pojemność bucket (maksymalna liczba requestów w jednorazowym spike).

Przykład: rate=10/s, burst=50 — klient może wysłać 50 requestów jednocześnie, ale potem musi czekać 1/10s na każdy kolejny.

Adaptive burst:

SYLION implementuje adaptive burst control: w godzinach szczytu (definiowanych przez historical traffic patterns) burst limit jest automatycznie obniżany o 30% aby zapewnić fair share. Adaptacja oparta na metrykach z Prometheus/VictoriaMetrics — analiza p95 latencji i error rate.

Connection-level throttling:

Oprócz rate limiting na poziomie HTTP, API Gateway egzekwuje limity połączeń TCP: - Max concurrent connections per IP: 100 (external), 1000 (internal). - Max requests per connection (HTTP/2): 1000. - Idle connection timeout: 60s (external), 300s (internal).

Slowloris protection:

Request header timeout: 10s. Request body timeout: 30s (chyba że endpoint przyjmuje upload — wtedy per-endpoint). Incomplete request → connection close.

56.3 Pasy priorytetowe — priorytet operacji bezpieczeństwa

Status: [N] Normatywny Odbiorca: Architekt, DevSecOps, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 56.1, 56.4, 67.2

W sytuacjach przeciążenia systemu, SYLION musi zapewnić priorytet dla operacji krytycznych dla bezpieczeństwa. System pasów priorytetowych (priority lanes) realizuje tę zasadę.

Definicja pasów:

Priorytet	Lane	Przykłady endpointów	Gwarancja
P0 — Critical	SECURITY	Token revocation, session termination, emergency lockdown, cert revocation	Zawsze obsługiwane — wyłączone z rate limitu
P1 — High	OPERATIONS	Session creation, auth, policy evaluation	95% requests <200ms
P2 — Normal	STANDARD	CRUD operations, data queries	90% requests <500ms
P3 — Low	BACKGROUND	Analytics, reporting, export, non-critical webhooks	Best effort, <2s

Implementacja:

Priority lanes realizowane przez weighted fair queuing na API Gateway. Każdy lane ma dedykowaną pulę workerów: - SECURITY: 20% zasobów (reserved, nie shared). - OPERATIONS: 40% zasobów. - STANDARD: 30% zasobów. - BACKGROUND: 10% zasobów.

Przy przeciążeniu, lane BACKGROUND jest throttlowany jako pierwszy (HTTP 503 z Retry-After). Lane SECURITY nie jest throttlowany nigdy — request security jest obsługiwany nawet kosztem degradacji innych lanes.

Klasyfikacja requestów:

Każdy request jest klasyfikowany do lane’a na podstawie: 1. Endpoint path + method (statyczna konfiguracja). 2. Nagłówek X-Priority (dozwolony wyłącznie dla serwisów wewnętrznych z mTLS — ignorowany dla requestów zewnętrznych). 3. SOC override: SOC może promować endpoint do lane SECURITY w runtime (np. podczas incydentu).

Monitoring:

Dashboard per-lane: latency p50/p95/p99, throughput, error rate, queue depth. Alert jeśli lane OPERATIONS przekroczy p95 >500ms przez >5 minut.

56.4 QoS dla endpointów krytycznych — policy engine, session broker

Status: [N] Normatywny Odbiorca: Architekt, DevSecOps, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 56.3, 56.5, 64.6

Endpointy krytyczne (policy engine, session broker, cert manager) wymagają dedykowanych gwarancji QoS, ponieważ ich niedostępność bezpośrednio wpływa na bezpieczeństwo i ciągłość działania platformy.

Session Broker:

Latency SLO: p99 <100ms dla session creation, <50ms dla session validation.

Availability SLO: 99.95% (max 4.3 min downtime/miesiąc).

Dedykowany pul połączeń do bazy danych (min 20, max 100 connections).

Circuit breaker na dependency (policy engine): jeśli policy engine niedostępny >5s → session broker stosuje cached policy (max cache age: 60s). Po 60s bez policy engine → nowe sesje blokowane, istniejące kontynuowane.

Auto-scaling: min 3 repliki (HA), max 10, scale trigger: CPU >60% lub p95 latency >80ms.

Policy Engine (OPA):

Latency SLO: p99 <20ms (decision evaluation).

Policy bundle refresh: co 30s. Stale bundle >5 min → alert.

Dedicated memory reservation: policy engine nie podlega eviction przez Kubernetes (PriorityClass: system-critical).

Preloaded policies: wszystkie polityki załadowane do pamięci przy starcie (nie lazy-load).

Certificate Manager (Vault):

Latency SLO: p99 <500ms dla cert issuance.

Availability SLO: 99.95%.

HA: 3-node Raft cluster w Zone 5. Unsealing: auto-unseal (AWS KMS / Azure Key Vault / GCP Cloud KMS, zależnie od deploymentu).

Backpressure: jeśli queue cert requests > 100 → alert + scale CA workers.

56.5 Definicje SLA API

Status: [N] Normatywny Odbiorca: Product Owner, SRE, Customer Success, Legal Wpływ na baseline: Krytyczny Powiązane rozdziały: 56.3, 56.4, 56.6

SLA (Service Level Agreement) dla API SYLION definiuje kontraktowe zobowiązania wobec operatorów, zróżnicowane per tier.

SLA per-tier:

Metryka	STANDARD	PRO	STATE
Availability (API)	99.9%	99.95%	99.95%
Latency p95 (CRUD)	<500ms	<300ms	<200ms
Latency p95 (auth)	<300ms	<200ms	<100ms
Error rate (5xx)	<0.1%	<0.05%	<0.01%
Planned maintenance window	4h/miesiąc	2h/miesiąc	0h (rolling updates)
Incident response time	4h	1h	15min
RTO (Recovery Time Objective)	4h	1h	15min
RPO (Recovery Point Objective)	1h	15min	1min

Wyłączenia SLA:

Siła wyższa (force majeure).

Działania klienta powodujące przeciążenie (powyżej kontraktowych limitów).

Zaplanowane okna serwisowe (zgłoszone z 72h wyprzedzeniem).

Incydenty bezpieczeństwa wymagające emergency shutdown.

Pomiar:

Availability mierzona jako: (total_minutes - downtime_minutes) / total_minutes * 100%. Downtime = okres, w którym >5% requestów danego tier zwraca HTTP 5xx.

Metryki zbierane przez external uptime monitor (poza infrastrukturą SYLION) — black-box monitoring.

Kompensacja:

Naruszenie SLA → credit na kolejny okres rozliczeniowy: 10% za każde 0.1% poniżej SLA, max 30% monthly fee.

56.6 SLO i error budgets

Status: [N] Normatywny Odbiorca: SRE, DevSecOps, Product Owner Wpływ na baseline: Wysoki Powiązane rozdziały: 56.5, 56.7, 68.10

SLO (Service Level Objectives) są wewnętrznymi celami jakościowymi, bardziej restrykcyjnymi niż SLA — zapewniając bufor bezpieczeństwa.

SLO = SLA + margines:

Metryka	SLA (STATE)	SLO (wewnętrzny)	Error Budget
Availability	99.95%	99.995%	2.6 min/miesiąc
Latency p95	<200ms	<150ms	—
Error rate	<0.01%	<0.005%	50% SLA budget

Error Budget policy:

Error budget = dozwolona ilość błędów/downtime zanim SLO zostanie naruszone. Mechanizm:

Error budget obliczany monthly: budget = 1 - SLO × total requests/minutes.

Dashboard: real-time error budget burn rate.

Jeśli >50% budget skonsumowane w pierwszej połowie miesiąca → freeze deploymentów (tylko hotfixes).

Jeśli >80% budget skonsumowane → incident response: SRE team przegląd, root cause analysis.

Jeśli budget wyczerpany (100%) → full freeze + postmortem + action items przed wznowieniem deploymentów.

Error budget jako narzędzie balansujące:

Error budget balansuje prędkość rozwoju (feature velocity) z niezawodnością. Zespoły z niewykorzystanym error budgetem mogą podejmować więcej ryzyka (nowe feature'y, eksperymenty). Zespoły z wyczerpanym budżetem muszą skupić się na stabilności.

56.7 Backpressure

Status: [N] Normatywny Odbiorca: Backend Developer, SRE, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 52.6, 56.1, 56.8

Backpressure to mechanizm, w którym przeciążony serwis sygnalizuje upstream aby zmniejszył wolumen requestów. W SYLION backpressure jest implementowane na trzech poziomach.

Poziom 1 — HTTP (synchroniczny):

Przeciążony serwis zwraca HTTP 503 Service Unavailable z Retry-After header. API Gateway respektuje Retry-After i buforuje requesty (max queue depth: 1000 per-endpoint). Jeśli queue overflow → HTTP 503 propagowany do klienta.

Poziom 2 — gRPC (synchroniczny):

gRPC serwis zwraca status UNAVAILABLE (code 14) z metadata retry-after-ms. Envoy sidecar implementuje automatic retry z exponential backoff (patrz 56.8). Max retries: 3.

Poziom 3 — Event bus (asynchroniczny):

Konsument przestaje commitować offseety (Kafka) lub acknowledgewać wiadomości (NATS). Broker wstrzymuje dostarczanie nowych wiadomości do tego konsumenta. Alert generowany po 15 min backpressure.

Health-based load balancing:

Envoy load balancer uwzględni health score serwisu przy routingu. Serwis raportuje health score (0.0–1.0) na basic /healthz endpoint. Score <0.5 → serwis otrzymuje 50% mniej ruchu. Score <0.2 → serwis wyłączony z rotacji (drain).

Circuit Breaker:

Każdy serwis klient implementuje circuit breaker (Envoy outlier detection): - Open po 5 consecutive failures lub >50% error rate w 60s window. - Half-open po 30s (1 test request). - Close po 3 successful requests.

Stan circuit breaker logowany i widoczny na service mesh dashboard.

56.8 Wzorce retry — exponential backoff, jitter

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps Wpływ na baseline: Wysoki Powiązane rozdziały: 52.7, 56.7, 65.10

Retry musi być implementowany w sposób kontrolowany aby nie powodować thundering herd (cascading overload). SYLION wymaga exponential backoff z full jitter.

Formuła:

sleep = random(0, min(max_delay, base_delay * 2^attempt))

Parametry domyślne: - base_delay: 100ms - max_delay: 30s - max_attempts: 5

Retry per typ komunikacji:

Typ	Retryable errors	Max attempts	Backoff
REST (external)	429, 503, timeout	5	Exponential + jitter
REST (internal)	429, 502, 503, timeout	3	Exponential + jitter
gRPC	UNAVAILABLE, DEADLINE_EXCEEDED	3	Exponential + jitter
Webhook delivery	Non-2xx, timeout	6	Fixed schedule (52.7)
Event processing	Consumer exception	5	Exponential + jitter → DLQ

Retry budget:

Globalna kontrola: max 20% requestów do danego serwisu może być retries. Jeśli retry ratio >20% → circuit breaker open (serwis jest prawdopodobnie down, retries pogarszają sytuację).

Idempotency requirement:

Retry jest bezpieczny wyłącznie dla operacji idempotentnych. Operacje nie-idempotentne (POST bez Idempotency-Key) nie podlegają automatic retry — klient musi sam zdecydować. W SYLION POST z Idempotency-Key (patrz 52.3) jest safe-to-retry.

Hedged requests:

Dla operacji read o niskiej latencji (np. policy evaluation), SYLION dopuszcza hedged requests: klient wysyła request do dwóch replik jednocześnie i akceptuje pierwszą odpowiedź. Dozwolone wyłącznie dla operacji GET/HEAD i tylko wewnętrznie.

Rozdział 57. Modele danych, schematy i migracje

57.1 Encje główne — pełne schematy

Status: [N] Normatywny Odbiorca: Backend Developer, Data Engineer, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 52.4, 53.1, 57.2

Model danych SYLION obejmuje następujące encje główne (core entities). Każda encja jest zdefiniowana z pełnym zestawem atrybutów, typów i constraintów.

Operator:

CREATE TABLE operators (id UUID PRIMARY KEY DEFAULT gen_random_uuid(), external_id VARCHAR(128) UNIQUE NOT NULL, name VARCHAR(256) NOT NULL, tier VARCHAR(16) NOT NULL CHECK (tier IN ('STANDARD', 'PRO', 'STATE')), status VARCHAR(32) NOT NULL CHECK (status IN ('ACTIVE', 'SUSPENDED',

```
'PENDING_APPROVAL', 'DEACTIVATED')), max_users INTEGER NOT NULL DEFAULT 10, max_environments INTEGER NOT NULL DEFAULT 1, contact_email VARCHAR(256) NOT NULL, metadata JSONB DEFAULT '{}', created_at TIMESTAMPTZ NOT NULL DEFAULT now(), updated_at TIMESTAMPTZ NOT NULL DEFAULT now(), suspended_at TIMESTAMPTZ, suspended_by UUID REFERENCES admin_users(id), suspension_reason TEXT );
```

Environment (środowisko operatora):

```
CREATE TABLE environments ( id UUID PRIMARY KEY DEFAULT gen_random_uuid(), operator_id UUID NOT NULL REFERENCES operators(id), name VARCHAR(256) NOT NULL, status VARCHAR(32) NOT NULL CHECK (status IN ('PROVISIONING', 'ACTIVE', 'SUSPENDED', 'DESTROYING')), zone VARCHAR(8) NOT NULL DEFAULT 'zone3', resource_limits JSONB NOT NULL, network_policy JSONB NOT NULL, created_at TIMESTAMPTZ NOT NULL DEFAULT now(), updated_at TIMESTAMPTZ NOT NULL DEFAULT now(), UNIQUE (operator_id, name) );
```

Session:

```
CREATE TABLE sessions ( id UUID PRIMARY KEY DEFAULT gen_random_uuid(), environment_id UUID NOT NULL REFERENCES environments(id), operator_id UUID NOT NULL REFERENCES operators(id), user_id UUID NOT NULL, session_type VARCHAR(32) NOT NULL CHECK (session_type IN ('DESKTOP', 'APP', 'BROWSER', 'TERMINAL')), status VARCHAR(32) NOT NULL CHECK (status IN ('INITIALIZING', 'ACTIVE', 'PAUSED', 'TERMINATED')), broker_node VARCHAR(128), workload_id UUID, started_at TIMESTAMPTZ NOT NULL DEFAULT now(), terminated_at TIMESTAMPTZ, termination_reason VARCHAR(64), last_activity_at TIMESTAMPTZ NOT NULL DEFAULT now(), ip_address INET, user_agent TEXT, metadata JSONB DEFAULT '{}'); CREATE INDEX idx_sessions_operator ON sessions(operator_id, status); CREATE INDEX idx_sessions_env ON sessions(environment_id, status);
```

Workload (microVM):

```
CREATE TABLE workloads ( id UUID PRIMARY KEY DEFAULT gen_random_uuid(), environment_id UUID NOT NULL REFERENCES environments(id), operator_id UUID NOT NULL REFERENCES operators(id), workload_type VARCHAR(32) NOT NULL CHECK (workload_type IN ('MICROVM', 'CONTAINER', 'APP_STREAM')), image_ref VARCHAR(512) NOT NULL, image_hash VARCHAR(128) NOT NULL, status VARCHAR(32) NOT NULL CHECK (status IN ('PENDING', 'RUNNING', 'STOPPED', 'FAILED', 'DESTROYED')), host_node VARCHAR(128), cpu_cores INTEGER NOT NULL, memory_mb INTEGER NOT NULL, sev_snp_enabled BOOLEAN NOT NULL DEFAULT true, attestation JSONB, created_at TIMESTAMPTZ NOT NULL DEFAULT now(), destroyed_at TIMESTAMPTZ );
```

Policy:

```
CREATE TABLE policies ( id UUID PRIMARY KEY DEFAULT gen_random_uuid(), name VARCHAR(256) NOT NULL, policy_type VARCHAR(32) NOT NULL CHECK (policy_type IN ('NETWORK', 'ACCESS', 'SESSION', 'CDR', 'EGRESS', 'RETENTION')), scope VARCHAR(32) NOT NULL CHECK (scope IN ('GLOBAL', 'TIER', 'OPERATOR', 'ENVIRONMENT')), scope_target UUID, version INTEGER NOT NULL DEFAULT 1, policy_document JSONB NOT NULL, status VARCHAR(16) NOT NULL CHECK (status IN ('DRAFT', 'ACTIVE', 'ARCHIVED')), created_by UUID NOT NULL, approved_by UUID, created_at TIMESTAMPTZ NOT NULL DEFAULT now(), activated_at TIMESTAMPTZ, archived_at TIMESTAMPTZ );
```

AuditLog:

```
CREATE TABLE audit_logs ( id UUID PRIMARY KEY DEFAULT gen_random_uuid(), timestamp TIMESTAMPTZ NOT NULL DEFAULT now(), actor_id UUID NOT NULL, actor_type VARCHAR(32) NOT NULL CHECK (actor_type IN ('USER', 'SERVICE', 'SYSTEM', 'SOC')), action VARCHAR(128) NOT NULL, resource_type VARCHAR(64) NOT NULL, resource_id UUID, operator_id UUID, zone VARCHAR(8), result VARCHAR(16) NOT NULL CHECK (result IN ('SUCCESS', 'FAILURE', 'DENIED')), details JSONB, ip_address INET, trace_id VARCHAR(64), hash_chain VARCHAR(128) NOT NULL, previous_hash VARCHAR(128) NOT NULL ) PARTITION BY RANGE (timestamp);
```

Tabela audit_logs jest partycjonowana po timestamp (monthly partitions) z retencją zgodną z polityką (patrz 58.4). Kolumny hash_chain i previous_hash zapewniają integralność łańcucha (WORM + hash chains).

57.2 Relacje

Status: [N] Normatywny Odbiorca: Backend Developer, Data Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 57.1, 57.3, 52.4

Relacje między encjami głównymi odzwierciedlają model domenowy SYLION z wyraźnymi granicami bounded contextów.

Diagram relacji (ERD — tekstowy):

```
Operator 1——* Environment 1——* Session | | | | 1——1 Workload | | | | * Workload | |——* Policy (scope=OPERATOR) | |——* AuditLog
(operator_id) Policy (scope=GLOBAL/TIER) ———> applies to ———> Operator (per tier) Certificate 1——1 Operator | Environment | Service Integration 1——1
Operator
```

Reguły integralności referencyjnej:

Usunięcie operatora: soft delete (status=DEACTIVATED). Fizyczne usunięcie po retencji (30 dni STANDARD, 90 dni PRO, 365 dni STATE). Kaskada: environments → suspended, sessions → terminated, workloads → destroyed.

Usunięcie environment: fizyczne dopiero gdy wszystkie sesje i workloady zakończone + dane retencyjne wygasły.

Session nie może istnieć bez environment i operator.

Workload może istnieć bez sesji (pre-provisioned workload).

Cross-context references:

Referencje między bounded contexts (np. session → policy) realizowane przez identyfikatory (UUID), nie przez foreign key w bazie danych. Każdy bounded context posiada własną bazę danych (database-per-service). Spójność zapewniona przez event-driven eventual consistency.

Tenant isolation:

Wszystkie zapytania do bazy danych muszą zawierać filtr operator_id (tenant isolation na poziomie danych). Row-Level Security (RLS) w PostgreSQL jest wymagany jako dodatkowa warstwa ochrony:

```
ALTER TABLE sessions ENABLE ROW LEVEL SECURITY; CREATE POLICY tenant_isolation ON sessions USING (operator_id = current_setting('app.operator_id')::UUID);
```

57.3 Schematy OLTP

Status: [N] Normatywny Odbiorca: Backend Developer, DBA Wpływ na baseline: Wysoki Powiązane rozdziały: 57.1, 57.4, 58.1

Schematy OLTP (Online Transaction Processing) są zoptymalizowane pod kątem operacji transakcyjnych: tworzenie sesji, aktualizacja statusów, walidacja polityk.

Zasady projektowania OLTP w SYLION:

Normalizacja: schematy OLTP w 3NF (Third Normal Form) minimum. Denormalizacja dozwolona wyłącznie z uzasadnieniem wydajnościowym i zatwierdzeniem DBA.

Indeksy: każda tabela musi mieć indeks na operator_id (tenant filter) i status (najczęstszy filtr). Composite indexes dla typowych query patterns. Partial indexes dla status = 'ACTIVE' (majority of queries).

Partycjonowanie: tabele z >10M wierszy muszą być partycjonowane (range by timestamp lub hash by operator_id).

Connection pooling: PgBouncer (transaction mode) obowiązkowy. Max connections per-service: 20. Pooler deployowany jako sidecar.

Transakcje: SERIALIZABLE isolation level dla operacji krytycznych (session creation, policy activation). READ COMMITTED dla odczytów.

Timeouts: Statement timeout: 10s (domyślnie). Lock timeout: 5s. Idle-in-transaction timeout: 30s.

Database-per-service:

Każdy bounded context posiada dedykowaną bazę danych PostgreSQL: - sylion-sessions-db — sesje, aktywne workloady. - sylion-operators-db — operatorzy, environments, konfiguracja. - sylion-policies-db — polityki, reguły. - sylion-audit-db — logi audytowe (WORM). - sylion-certs-db — certyfikaty, klucze publiczne.

Izolacja baz danych zapewnia blast radius reduction — kompromitacja jednej bazy nie daje dostępu do danych innych kontekstów.

57.4 Schematy OLAP

Status: [R] Rekomendowany Odbiorca: Data Engineer, Architekt, Product Analytics Wpływ na baseline: Średni Powiązane rozdziały: 57.3, 58.5, 58.7

Schematy OLAP (Online Analytical Processing) służą do analizy danych operacyjnych: raporty wykorzystania, trendy sesji, analiza incydentów.

Architektura:

Dane z baz OLTP są replikowane do hurtowni danych (data warehouse) za pomocą CDC (Change Data Capture — Debezium) → broker zdarzeń → ETL → OLAP store. Opóźnienie replikacji: <5 minut.

Model wymiarowy (Star Schema):

Fakt: fact_sessions — jedno zdarzenie sesji (utworzenie, terminacja).

Kolumna	Typ	Opis
session_id	UUID	PK
operator_key	FK	→ dim_operators
time_key	FK	→ dim_time
environment_key	FK	→ dim_environments
session_type	VARCHAR	DESKTOP, APP, etc.
duration_seconds	INTEGER	Czas trwania sesji
termination_reason	VARCHAR	Powód zakończenia
bytes_transferred	BIGINT	Transfer danych

Wymiary: dim_operators (operator, tier, status), dim_time (data, godzina, dzień tygodnia), dim_environments (environment, zone, resource limits).

Bezpieczeństwo OLAP:

Dane w OLAP nie zawierają PII (Personally Identifiable Information) — operator_id jest pseudonimizowany.

Dostęp do OLAP wyłącznie z Zone 4 (shared services) przez dedykowany serwis analityczny.

Dane OLAP szyfrowane at-rest (AES-256-GCM).

Retencja danych OLAP: 24 miesiące (konfigurowalne per-deployment).

57.5 Wersjonowanie schematów bazy danych

Status: [N] Normatywny Odbiorca: Backend Developer, DBA, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 57.6, 57.7, 54.6

Schematy baz danych są wersjonowane za pomocą narzędzia migracji (Flyway lub Liquibase — wybór per-deployment, konsekwentny w obrębie deploymentu).

Konwencja nazewnictwa migracji:

V{version}__{description}.sql

Przykłady: - V001__create_operators_table.sql - V002__create_environments_table.sql - V015__add_sev_snp_column_to_workloads.sql - V016__add_index_sessions_operator_status.sql

Wersje są sekwencyjne (integer, nie timestamp). Opis w snake_case. Każda migracja jest atomowa — jedna zmiana logiczna per plik.

Niezmiennosc migracji:

Migracja raz zastosowana w produkcji jest niezmienna (immutable). Modyfikacja zastosowanej migracji jest zabroniona — poprawki realizowane przez nową migrację. Checksum migracji weryfikowany przez Flyway przy każdym uruchomieniu.

Przegląd migracji:

Każda migracja musi przejść przegląd DBA przed merge. Przegląd weryfikuje: - Kompatybilność z bieżącą wersją kodu (forward-compatible). - Brak blokujących operacji na dużych tabelach (np. ALTER TABLE ... ADD COLUMN NOT NULL bez DEFAULT na tabeli >1M wierszy). - Poprawność indeksów (CONCURRENTLY dla dużych tabel). - Zgodność z polityką retencji (partycjonowanie jeśli wymagane).

57.6 Migracje forward i rollback

Status: [N] Normatywny Odbiorca: Backend Developer, DBA, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 57.5, 57.7, 54.6

Strategia expand-contract (expand-and-contract):

SYLION wymaga strategii expand-contract dla wszystkich zmian schematów, zapewniając zero-downtime migrations:

Expand: nowa migracja dodaje nowe elementy (kolumna, tabela, indeks) bez usuwania starych. Stary kod nadal działa.

Migrate: nowa wersja kodu zaczyna używać nowych elementów. Stary kod nadal działa (dual-write / dual-read).

Contract: po pełnym wdrożeniu nowej wersji i potwierdzeniu stabilności (min 48h) — migracja usuwająca stare elementy.

Przykład: zmiana nazwy kolumny user_name → display_name:

V020__add_display_name_column.sql: ALTER TABLE users ADD COLUMN display_name VARCHAR(256);

Kod v2.5: zapisuje do obu kolumn, czyta z display_name (fallback na user_name).

V021__backfill_display_name.sql: UPDATE users SET display_name = user_name WHERE display_name IS NULL; (batch po 10000).

Kod v2.6: czyta i pisze wyłącznie display_name.

V022__drop_user_name_column.sql: ALTER TABLE users DROP COLUMN user_name;

Rollback:

Flyway nie wspiera natywnego rollback. SYLION wymaga: - Każda migracja forward ma odpowiadający skrypt undo w osobnym pliku:

U020__undo_add_display_name.sql. - Rollback jest testowany w pipeline CI na kopii bazy danych. - Rollback w produkcji wymaga dual authorization (Four-Eyes) i jest logowany w audit log. - Rollback jest dopuszczalny wyłącznie w fazie expand (przed contract). Po contract — rollback wymaga nowej migracji forward.

Timeout:

Migracje w produkcji mają timeout: 5 minut dla DDL, 30 minut dla DML (backfill). Przekroczenie → automatyczny rollback.

57.7 Ewolucja danych contract-first

Status: [N] Normatywny Odbiorca: Architekt, Backend Developer, Data Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 53.1, 54.6, 57.5

Podejście contract-first oznacza, że schemat API (kontrakt) jest źródłem prawdy, a schemat bazy danych jest pochodną kontraktu. Ewolucja danych zaczyna się od zmiany kontraktu, nie od zmiany schematu.

Workflow:

Zmiana wymagań biznesowych → propozycja zmiany kontraktu (OpenAPI/Protobuf).

Analiza kompatybilności kontraktu (patrz 53.8, 54.2).

Projektowanie migracji bazy danych zgodnej z nowym kontraktem (expand-contract).

Implementacja kodu zgodnego z nowym kontraktem.

Testy kontraktowe + testy migracji.

Deployment: migracja → kod → weryfikacja.

Mapowanie kontrakt → schemat:

Nie jest wymagane mapowanie 1:1. Kontrakt API może eksponować zagregowany widok danych przechowywanych w wielu tabelach. Mapowanie dokumentowane w ADR (Architecture Decision Record).

57.8 Bramki kompatybilności

Status: [N] Normatywny Odbiorca: DevSecOps, Backend Developer, QA Wpływ na baseline: Wysoki Powiązane rozdziały: 53.8, 57.6, 57.9

Bramki kompatybilności (compatibility gates) to automatyczne kontrole w pipeline CI/CD, które blokują deployment w przypadku wykrycia niekompatybilnej zmiany.

Gate 1 — Schema compatibility:

oasdiff / buf breaking — porównanie kontraktów API. Breaking change → FAIL.

Gate 2 — Database migration safety:

Analiza migracji SQL pod kątem bezpieczeństwa: - Brak DROP TABLE bez flagi --force-destructive. - Brak ALTER TABLE ... NOT NULL bez DEFAULT. - Brak CREATE INDEX bez CONCURRENTLY na tabelach >100K wierszy. - Czas wykonania migracji na kopii bazy <5 min.

Narzędzie: squawk (PostgreSQL linter) lub odpowiednik.

Gate 3 — Contract test pass:

Pact verification — wszystkie kontrakty konsumentów muszą przechodzić.

Gate 4 — Rollback test:

Skrypt undo musi wykonać się poprawnie na kopii bazy z zastosowaną migracją forward.

Wszystkie 4 gates muszą przejść aby PR mógł być zmergowany. Bypass wyłącznie za zgodą DBA + Security Lead + dual authorization.

57.9 Testowanie migracji

Status: [N] Normatywny Odbiorca: QA, Backend Developer, DBA Wpływ na baseline: Wysoki Powiązane rozdziały: 57.6, 57.8, 70.6

Środowisko testowe:

Migracje testowane na kopii bazy produkcyjnej (anonimizowanej — PII usunięte/zaszyfrowane). Kopia odświeżana co 7 dni. Rozmiar danych: minimum 10% produkcji (sample).

Testy:

Forward migration: migracja wykonuje się bez błędów w limicie czasowym.

Rollback migration: undo script przywraca schemat do stanu przed migracją.

Data integrity: po migracji forward — dane nie są utracone, relacje spójne.

Application compatibility: stary kod działa z nowym schematem (forward-compatible). Nowy kod działa ze starym schematem (rollback scenario).

Performance: typowe zapytania (top 10 by frequency) nie degradują > 10% po migracji.

Concurrent access: migracja nie blokuje operacji CRUD na > 5s (lock analysis).

57.10 Zależności schemat-do-feature

Status: [R] Rekomendowany Odbiorca: Product Owner, Backend Developer, Architekt Wpływ na baseline: Średni Powiązane rozdziały: 57.5, 57.7, 54.4

Matryca zależności dokumentuje, które feature'y zależą od których zmian schematu i odwrotnie.

Format dokumentacji:

migration: V025__add_pqc_key_column feature: PQC hybrid key exchange depends_on: - V024__extend_certificate_table blocks: - feature/pqc-kem - feature/cnsa-2.0-compliance rollback_safe: true rollback_deadline: 2026-06-01 owner: security-team

Rejestr:

Matryca utrzymywana w repozytorium schema-feature-map jako pliki YAML. Przegląd przy planowaniu sprintu — identyfikacja zależności między zespołami.

Feature nie może być oznaczony jako „ready for development” dopóki wymagane migracje nie są zmergowane i zdeployowane na staging.

Rozdział 58. Magazyny danych i strategię przechowywania

58.1 RDBMS — PostgreSQL dla danych operacyjnych

Status: [N] Normatywny Odbiorca: Backend Developer, DBA, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 57.1, 57.3, 58.10

PostgreSQL (wersja 16+) stanowi obowiązkowy RDBMS dla danych operacyjnych (OLTP) w SYLION. Wybór PostgreSQL wynika z: otwartego kodu źródłowego (brak vendor lock-in), wsparcia dla Row-Level Security (tenant isolation), natywnego JSONB (flexible metadata), partycjonowania i dojrzałego ekosystemu replikacji.

Deployment per bounded context:

Każdy bounded context (sessions, operators, policies, audit, certificates) posiada dedykowaną instancję PostgreSQL: - Primary + minimum 1 synchronous replica (HA). - Asynchronous replica dla read-heavy workloads (audit queries, reporting). - WAL archiving do object store (point-in-time recovery).

Hardening:

TLS obowiązkowe dla wszystkich połączeń (no plaintext). Certyfikaty zarządzane przez Vault PKI.

Authentication: scram-sha-256 (nie md5). Certificate-based auth preferowane.

Network: dostęp wyłącznie z Zone 3/4 (mikroserwisy) — brak publicznego dostępu.

Audit: pgAudit extension aktywowany — logowanie DDL + DML na tabelach wrażliwych.

Encryption at-rest: LUKS (block-level) lub Transparent Data Encryption (TDE) jeśli dostępne.

Superuser disabled: brak bezpośredniego dostępu superuser. Operacje DDL przez migration pipeline.

Connection management:

PgBouncer w transaction mode jako sidecar. Max connections: limitowane per-service (20 domyślnie). Overflow → HTTP 503 z backpressure (patrz 56.7). Statement timeout: 10s domyślnie, 60s dla raportów (per-role).

Backup:

Full backup: daily (pg_basebackup).

WAL archiving: continuous (pgBackRest → object store).

PITR (Point-in-Time Recovery): gwarantowane do 7 dni wstecz.

Backup encryption: AES-256-GCM z kluczem przechowywanym w Vault.

Backup verification: weekly restore test na isolated environment.

58.2 NoSQL — document store i key-value

Status: [N] Normatywny Odbiorca: Backend Developer, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 58.1, 58.9, 57.1

Document Store (policy configs):

MongoDB lub PostgreSQL JSONB (preferowany — redukcja technologii) dla dokumentów konfiguracyjnych o zmiennej strukturze: szablon polityk, konfiguracje adapterów integracyjnych, definicje workflow. Jeśli MongoDB: replica set (3 nody), authentication (SCRAM-SHA-256), authorization (RBAC), TLS, encryption at-rest (WiredTiger encrypted storage engine).

Key-Value Store (sessions, cache):

Redis (wersja 7+) jako primary key-value store: - Session cache: aktywne sesje (TTL = session timeout + 5 min buffer). - Rate limiting counters: sliding window per-client (patrz 56.1). - Idempotency keys: hash request → response (TTL 24h, patrz 52.3). - Feature flags: real-time feature toggles. - Distributed locks: Redlock algorithm dla operacji wymagających koordynacji.

Redis hardening:

TLS obowiązkowe. AUTH z hasłem >32 znaków (zarządzane przez Vault).

No KEYS * command w produkcji (disabled via rename-command).

maxmemory-policy: allkeys-lru (dla cache) lub noeviction (dla critical data).

Redis Sentinel lub Redis Cluster (HA). Min 3 nody (1 primary + 2 replicas).

AOF persistence: enabled z fsync co 1s. RDB snapshots: co 15 min.

Network: dostęp wyłącznie z Zone 3/4. Brak publicznego dostępu.

Zakaz:

Redis nie może być jedynym magazynem danych (single source of truth) dla danych krytycznych. Redis jest cache/auxiliary store — dane krytyczne muszą być persystowane w PostgreSQL.

58.3 Time-series — Prometheus/VictoriaMetrics dla metryk

Status: [N] Normatywny Odbiorca: SRE, DevSecOps, Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 56.5, 56.6, 68.10

Metryki platformy przechowywane w time-series database: VictoriaMetrics (preferowany — lepsze skalowanie i kompresja) lub Prometheus (kompatybilny).

Kategorie metryk:

Infrastructure: CPU, memory, disk, network per-node, per-pod.

Application: request latency (histogram), error rate, throughput per-endpoint.

Business: active sessions, active operators, session duration, CDR scans.

Security: auth failures, policy denials, cert expirations, anomaly scores.

Labeling conventions:

```
sylicon_session_duration_seconds{operator="op-123", tier="STATE", zone="zone3", env="env-456"}
sylicon_api_request_duration_seconds{method="POST", path="/v2/sessions", status="201"}
sylicon_security_auth_failures_total{reason="token_expired", source_ip="masked"}
```

Obowiązkowe label: operator (pseudonimizowany hash, nie raw ID), zone, tier. Label source_ip musi być maskowany (hashed) — ochrona PII.

Retencja:

Raw metrics: 15 dni.

Downsampled (5min avg): 90 dni.

Downsampled (1h avg): 365 dni.

Alerting:

Reguły alertów definiowane w Prometheus/VictoriaMetrics alerting rules (YAML) przechowywane w repozytorium monitoring-config. Alerty routowane do: - SOC: security alerts (auth failures >threshold, anomaly detection). - SRE: infrastructure alerts (CPU >80%, disk >85%, latency SLO breach). - On-call: availability alerts (5xx >SLO threshold).

HA:

VictoriaMetrics w cluster mode (vmselect + vminsert + vmstorage). Min 3 vmstorage nodes. Replication factor: 2.

58.4 Log stores — niezmiennie, WORM-compatible

Status: [N] Normatywny Odbiorca: Security Architect, SOC, Compliance, DBA Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.8, 66.11, 58.7

Logi audytowe i bezpieczeństwa muszą być przechowywane w magazynie spełniającym wymagania WORM (Write Once Read Many) z kryptograficznym łańcuchem hashów.

Architektura:

[Mikroserwis] → [Log Collector (Fluentd/Vector)] → [Hash Chain Engine] → [WORM Storage] ↓ [Hash publikowany do zewnętrznego timestamping]

Hash Chain Engine:

Każdy wpis logu audytowego zawiera: - hash_chain: SHA-256 hash bieżącego wpisu (timestamp + actor + action + details). - previous_hash: hash poprzedniego wpisu w łańcuchu. - Pierwszy wpis w łańcuchu: previous_hash = SHA-256("GENESIS").

Weryfikacja integralności: skrypt walidacyjny iteruje łańcuch od genesis i weryfikuje, że hash_chain[n] = SHA-256(previous_hash[n] + data[n]). Brak luk (gap detection).

WORM Storage:

Opcje implementacji: 1. PostgreSQL z immutable triggers: trigger BEFORE UPDATE/DELETE na tabeli audit_logs → RAISE EXCEPTION. Superuser disabled. 2. Object store z WORM policy: AWS S3 Object Lock (Compliance Mode), Azure Blob Immutable Storage, MinIO Object Locking. 3. Dedicated log store: Loki z immutable storage backend.

Szyfrowanie:

At-rest: AES-256-GCM. Klucz zarządzany przez BYO-KMS (operator dostarcza klucz szyfrowania logów) lub Vault.
Operator STATE może dostarczyć własny klucz (BYO-KMS) — SYLION nie ma dostępu do plaintext logów operatora.

Retencja:

Tier	Retencja audytowa	Retencja operacyjna
STANDARD	12 miesięcy	30 dni
PRO	24 miesiące	90 dni
STATE	60 miesięcy (lub zgodnie z regulacją)	365 dni

Selective retention:

Operator może zdefiniować politykę selective retention: np. logi sesji desktop — 24 miesiące, logi admin — 60 miesięcy, logi CDR — 36 miesięcy. Granularność: per-action-type.

58.5 Object stores — szyfrowane, dla backupów, artefaktów, CDR staging

Status: [N] Normatywny Odbiorca: DevSecOps, Backend Developer, SRE Wpływ na baseline: Wysoki Powiązane rozdziały: 58.4, 58.6, 69.4

Object store (S3-compatible: AWS S3, MinIO, Ceph RGW) służy jako magazyn: - Backupów baz danych (encrypted). - Artefaktów CI/CD (obrazy kontenerów po skanowaniu, SBOM). - CDR staging (pliki przed i po sanityzacji). - Logów eksportowanych (WORM). - Raportów compliance.

Szyfrowanie:

Server-Side Encryption (SSE): AES-256-GCM. Każdy bucket z osobnym kluczem (KEK w Vault, DEK per-object).

Opcjonalnie: Client-Side Encryption (CSE) dla najwrażliwszych danych (operator BYO-KMS).

Brak plaintext objects w produkcji — enforcement przez bucket policy (deny PutObject bez encryption).

Bucket policies:

Deny public access (BlockPublicAccess: enabled).

Deny unencrypted uploads.

Lifecycle: automatic transition (hot → warm → cold → delete) zgodnie z retencją.

Versioning: enabled dla backupów (ochrona przed nadpisaniem/usunięciem).

WORM: Object Lock (Compliance Mode) dla log exports i evidence.

Access logging: enabled (kto, kiedy, jaką operację na jakim obiekcie).

Izolacja per-operator:

Każdy operator posiada osobny prefix (virtual namespace): s3://sylicon-data/{operator_id}/. Bucket policy egzekwuje izolację — żaden serwis nie może czytać danych innego operatora bez jawnego uprawnienia.

CDR staging:

Pliki przesłane przez użytkowników trafiają do s3://sylicon-cdr-staging/{operator_id}/incoming/. CDR engine pobiera plik, sanityzuje, zapisuje wynik w s3://sylicon-cdr-staging/{operator_id}/sanitized/. Oryginał usuwany po sanityzacji (lub przenoszony do quarantine jeśli wykryto zagrożenie). Quarantine bucket: osobna retencja (30 dni), dostęp wyłącznie dla SOC.

58.6 Secret stores — HashiCorp Vault

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 66.1, 66.2, 55.3

HashiCorp Vault lub OpenBao (fork Vault, licencja MPL 2.0) stanowi obowiązkowy secret store w SYLION. Wszystkie tajemnice (secrets) muszą być przechowywane i zarządzane wyłącznie przez Vault.

Secrets engines w użyciu:

Engine	Zastosowanie
KV v2	Statyczne sekrety (API keys partnerów, konfiguracja integracji)
PKI	Certyfikaty TLS (service certs, mTLS, intermediate CA)
Transit	Encryption-as-a-service (szyfrowanie danych, podpisy JWT)

Database	Dynamiczne credentials do baz danych (TTL-based)
AWS/Azure/GCP	Dynamiczne credentials do cloud provider
TOTP	Generowanie TOTP dla emergency access
SSH	Podpisywanie kluczy SSH (ephemeral access)

- Deployment:
- 3-node Raft cluster w Zone 5 (management plane).
 - Auto-unseal: AWS KMS / Azure Key Vault / GCP Cloud KMS (zależnie od deploymentu).
 - Backup: Raft snapshots co 1h → encrypted object store.
 - HA: automatic leader election. Failover <10s.
- Access control:
- Vault policies (HCL) egzekwują least privilege: każdy serwis ma policy ograniczone do ścieżek, które potrzebuje.
 - Authentication: Kubernetes auth (service account JWT), AppRole (CI/CD), OIDC (admin users).
 - Audit: pełne logowanie operacji (każdy read, write, list, delete). Audit logs → WORM store.
 - Namespace isolation: każda strefa (Zone 3, 4, 5) w osobnym Vault namespace.
- Dynamic secrets:
- Credentials do baz danych są dynamiczne (generowane on-demand przez Vault): - TTL: 1h (domyślnie). Renewable do max 24h. - Po wygaśnięciu → Vault automatycznie revokuje credentials (DROP ROLE). - Eliminacja long-lived credentials — główna mitygacja credential theft.

58.7 Search indexes — dla logów i audytu

- Status: [R] Rekomendowany Odbiorca: SOC, SRE, Compliance Wpływ na baseline: Średni Powiązane rozdziały: 58.4, 59.3, 67.1
- Indeksy wyszukiwania umożliwiają szybkie przeszukiwanie logów audytowych i operacyjnych. Realizacja: Elasticsearch/OpenSearch lub Loki (log aggregation).
- Architektura:
- [WORM Log Store] → [Index Pipeline (Vector/Logstash)] → [Search Index (OpenSearch)] ↓ [Kibana/Grafana UI]
- Dane w search index są kopią (nie źródłem prawdy). Źródło prawdy: WORM log store (58.4). Utrata search indexu nie oznacza utraty danych — rebuild z WORM store.
- Indeksowanie:
- Logi audytowe: indeksowane z opóźnieniem <30s.
 - Logi operacyjne: indeksowane z opóźnieniem <60s.
 - Pola indeksowane: timestamp, actor_id, action, resource_type, operator_id, zone, result, trace_id.
 - Full-text search na polu details (JSONB → text).
- Retencja w indexie:
- Index retencja ≤ WORM retencja. Index może mieć krótszą retencję (np. 90 dni w indexie, 60 miesięcy w WORM). Stare dane dostępne przez query do WORM store (wolniejsze, ale complete).
- Bezpieczeństwo:
- Search index szyfrowany at-rest.
 - Dostęp: SOC (full read), SRE (operational logs only), Compliance (audit logs only). RBAC egzekwowany przez OpenSearch Security plugin.
 - Tenant isolation: filtr operator_id obowiązkowy w każdym zapytaniu (document-level security).

58.8 Graph stores

- Status: [O] Opcjonalny Odbiorca: Security Analyst, SOC, Architekt Wpływ na baseline: Niski Powiązane rozdziały: 58.1, 64.1, 67.10
- Graph store (Neo4j lub Apache AGE jako extension PostgreSQL) może być wdrożony dla zaawansowanej analizy relacji i wykrywania anomalii.
- Zastosowania:
- Analiza lateral movement: modelowanie relacji między sesjami, użytkownikami, workloadami jako graf. Wykrywanie nietypowych ścieżek dostępu.
 - Dependency mapping: graf zależności między mikroservisami — analiza blast radius.
 - Access pattern analysis: graf relacji user → resource → action — wykrywanie privilege escalation.
 - Incident investigation: rekonstrukcja łańcucha zdarzeń (kill chain) jako graf.
- Implementacja:
- Apache AGE (extension PostgreSQL) preferowany — minimalizacja technologii, integracja z istniejącym PostgreSQL.
 - Dane importowane z audit log i telemetry (batch ETL, nie real-time).
 - Dostęp wyłącznie z Zone 4 (analitka) i Zone 5 (SOC tools).

58.9 Kiedy jaki typ magazynu jest dopuszczalny

Status: [N] Normatywny Odbiorca: Architekt, Backend Developer Wpływ na baseline: Wysoki Powiązane rozdziały: 58.1–58.8

Matryca decyzyjna:

Typ danych	Primary store	Secondary/cache	Niedozwolone
Dane operacyjne (CRUD)	PostgreSQL	Redis (cache)	MongoDB standalone
Konfiguracja polityk	PostgreSQL (JSONB)	Redis (cache)	Pliki lokalne
Sesje aktywne (state)	PostgreSQL	Redis (primary cache)	In-memory only
Logi audytowe	WORM (PostgreSQL + Object Store)	Search index	Non-WORM store
Metryki	VictoriaMetrics/Prometheus	—	PostgreSQL
Sekrety	Vault	Nigdy cache	Baza danych, pliki, env vars
Backupy	Object store (encrypted)	—	Dysk lokalny
Artefakty CI/CD	Object store (signed)	—	Dysk lokalny
CDR staging	Object store (isolated)	—	Shared filesystem
Search indexes	OpenSearch/Loki	—	PostgreSQL (perf)

Reguła: Każdy nowy typ danych wymaga jawnej decyzji storage z dokumentacją w ADR (Architecture Decision Record). Decyzja musi wskazywać: typ danych, wymagania (consistency, durability, latency, capacity, security), wybrany store, uzasadnienie.

58.10 Replikacja i modele spójności

Status: [N] Normatywny Odbiorca: Architekt, DBA, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 58.1, 58.6, 56.5

PostgreSQL:

Replikacja synchroniczna (synchronous_commit = on) dla primary operations: session creation, policy activation, audit log insert.

Replikacja asynchroniczna dla read replicas (reporting, analytics).

Failover: automatic (Patroni / CloudNativePG operator). Failover time <30s. RPO: 0 (sync replication — no data loss).

Redis:

Redis Sentinel: async replication. Możliwa utrata danych przy failover (max 1s writes). Akceptowalne dla cache/rate limiting.

Redis Cluster: dla horizontal scaling. Sharding by hash slot.

Vault:

Raft consensus: strongly consistent. No data loss at failover. Write quorum: majority (2/3 nodes).

Event Broker (Kafka/NATS):

Kafka: replication factor 3, min.insync.replicas = 2. Acks = all (producer). Gwarancja: no data loss (committed messages).

NATS JetStream: R3 (3 replicas). Ack policy: explicit.

Object Store:

Replication: cross-zone (min 2 AZ) lub cross-region (dla STATE tier disaster recovery).

Consistency: strong read-after-write consistency (S3, MinIO).

Model spójności per-operacja:

Operacja	Wymagana spójność
Session creation	Strong (sync PostgreSQL)
Policy evaluation	Eventual (cache max 60s)
Audit log write	Strong (sync + WORM)
Metric write	Eventual (async, lossy ok)
Secret read	Strong (Vault consensus)
CDR scan result	Strong (sync to PostgreSQL)

Rozdział 59. Integracje zewnętrzne i ekosystem

59.1 Integracje tożsamości — Azure AD, Okta, LDAP/AD

Status: [N] Normatywny Odbiorca: Identity Engineer, Architekt, Operator Admin Wpływ na baseline: Krytyczny Powiązane rozdziały: 55.1, 55.2, 59.10

SYLION integruje się z zewnętrznymi dostawcami tożsamości (Identity Providers — IdP) aby umożliwić operatorom korzystanie z istniejącej infrastruktury IAM.

Obsługiwane protokoły:

Protokół	Zastosowanie	Status
OIDC	Primary federation (Azure AD, Okta, Google Workspace)	[N]

SAML 2.0	Legacy IdP (ADFS, Shibboleth)	[R]
LDAP/LDAPS	Directory sync (Active Directory, OpenLDAP)	[R]
SCIM 2.0	User provisioning/deprovisioning	[R]

Azure AD (Entra ID) — integracja:

Rejestracja aplikacji SYLION w Azure AD (Enterprise Application).

Konfiguracja OIDC: client_id, client_secret (stored in Vault), redirect_uri, scopes.

Mapowanie grup Azure AD → role SYLION (operator-admin, soc-viewer, user).

Conditional Access: Azure AD Conditional Access Policies komplementarne (nie zastępujące) do polityk SYLION.

Token validation: SYLION weryfikuje id_token z Azure AD, mapuje claims, wydaje własny token SYLION.

Okta — integracja:

Analogiczna do Azure AD (OIDC). Dodatkowa konfiguracja: Okta SCIM provisioning → SYLION user lifecycle (create, update, deactivate, delete).

LDAP/AD — synchronizacja katalogowa:

LDAP connector deployowany w Zone 4 (adapter pattern — patrz 52.8).

Synchronizacja jednokierunkowa: LDAP → SYLION (SYLION nie modyfikuje AD).

Sync interval: co 15 minut (delta sync). Full sync: co 24h.

Bezpieczeństwo: LDAPS (TLS obowiązkowe). Bind account z minimalnymi uprawnieniami (read-only).

User deprovisioning: użytkownik usunięty/dezaktywowany w AD → automatyczna dezaktywacja w SYLION (max opóźnienie: 15 min).

Identity mapping:

Moduł Identity Mapping tłumaczy external identity (Azure AD object ID, Okta user ID) na internal SYLION identity. Mapping przechowywany w sylion-operators-db. Jedna external identity może być mapowana na jedną SYLION identity (1:1). Mapowanie jest per-operator — ten sam external user ID w dwóch operatorach to dwie różne SYLION identities.

59.2 Integracje cloud — AWS, GCP, Azure dla sovereign cloud

Status: [R] Rekomendowany Odbiorca: Architekt, DevSecOps, Operator Admin Wpływ na baseline: Wysoki Powiązane rozdziały: 58.6, 59.10, 64.8

SYLION jest deployment-agnostic i może działać on-premises, w chmurze publicznej lub w modelu hybrydowym. Integracje cloud zapewniają natywne wykorzystanie usług cloud provider w sposób kontrolowany.

AWS:

KMS: auto-unseal Vault, envelope encryption.

S3: object store (backupy, artefakty, CDR staging).

IAM: IRSA (IAM Roles for Service Accounts) — dynamiczne credentials.

CloudTrail: audit feed (supplementary, nie primary).

VPC: network isolation per-zone.

Azure:

Key Vault: auto-unseal Vault, key management.

Blob Storage: object store.

Managed Identity: credentials dla workloadów Azure.

Azure Monitor: supplementary telemetry.

VNet: network isolation.

GCP:

Cloud KMS: auto-unseal, encryption.

GCS: object store.

Workload Identity: credentials.

Sovereign cloud mode:

Dla operatorów STATE wymagających suwerenności danych: - Deployment w sovereign cloud region (EU, DE, PL). - BYO-KMS: operator zarządza kluczami. - No cross-region replication (dane nie opuszczają jurysdykcji). - No cloud-native monitoring (telemetria nie wysyłana do cloud provider). - Auditable: operator może zweryfikować, że dane nie opuszczają regionu.

59.3 Integracje SIEM/SOAR — Splunk, QRadar, Sentinel, Elastic

Status: [N] Normatywny Odbiorca: SOC, Security Architect, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 58.4, 58.7, 52.7

SYLION musi integrować się z zewnętrznymi systemami SIEM/SOAR operatora, dostarczając dane audytowe i zdarzenia bezpieczeństwa w standardowych formatach.

- Formaty eksportu:
- CEF (Common Event Format): kompatybilny z ArcSight, QRadar.
 - LEEF (Log Event Extended Format): kompatybilny z QRadar.
 - JSON (structured): kompatybilny z Splunk HEC, Elastic, Azure Sentinel.
 - Syslog (RFC 5424): uniwersalny transport.
- Mechanizmy dostarczania:
- Syslog forward: UDP/TCP/TLS syslog z SYLION log collector do SIEM. TLS obowiązkowy.
 - HTTP Event Collector (HEC): Splunk HEC, Elastic HTTP input. Bearer token auth.
 - Webhook: zdarzenia bezpieczeństwa wysyłane jako webhooks (patrz 52.7).
 - API pull: SIEM odpytuje SYLION API (GET /v2/audit-logs?since=...). Rate-limited (patrz 56.1).
 - Kafka connect: dedykowany Kafka topic sylion.*.security.* z connectors do SIEM.
- Kategorie zdarzeń eksportowanych:

Kategoria	Przykłady	Priorytet
Authentication	Login success/failure, MFA challenge, token revocation	HIGH
Authorization	Access denied, policy violation, scope escalation	HIGH
Session lifecycle	Session created/terminated/timeout	MEDIUM
Admin operations	Operator created/modified, policy changed, cert rotated	HIGH
Security alerts	Intrusion detected, anomaly, brute force	CRITICAL
Compliance	Four-Eyes approval, evidence export, audit access	HIGH

- Konfiguracja per-operator:
- Operator STATE może konfigurować: jakie kategorie zdarzeń eksportować, do którego SIEM, w jakim formacie, z jakim filtrem (np. tylko zdarzenia dotyczące swojego operatora). Konfiguracja przez panel administratora lub API.

59.4 Integracje płatności — dla zarządzania subskrypcjami

- Status: [R] Rekomendowany Odbiorca: Product Owner, Backend Developer, Finance Wpływ na baseline: Niski Powiązane rozdziały: 57.1, 59.10
- Integracja z platformą płatności (Stripe — preferowany, lub odpowiednik) do zarządzania subskrypcjami operatorów.
- Zakres integracji:
- Tworzenie subskrypcji (operator onboarding → Stripe customer + subscription).
 - Zmiana planu (tier upgrade/downgrade: STANDARD ↔ PRO ↔ STATE).
 - Fakturowanie (automatic invoicing via Stripe).
 - Webhook events: invoice.paid, invoice.payment_failed, customer.subscription.deleted.
- Bezpieczeństwo:
- Stripe API key przechowywany w Vault (nie w kodzie/config).
 - Webhook secret w Vault. Signature verification (patrz 52.7 pattern).
 - PCI DSS: SYLION nie przechowuje danych kart — Stripe tokenization. Scope PCI: SAQ-A.
 - Adapter pattern: stripe-adapter w Zone 4 (izolacja).
- Dane przechowywane w SYLION:
- Tylko: Stripe customer_id, subscription_id, tier, status, billing email. Nigdy: numer karty, CVV, billing address. Stripe jest jedynym procesorem danych płatniczych.

59.5 Integracje ERP/CRM — dla workloadów CRM klienta

- Status: [O] Opcjonalny Odbiorca: Architekt, Partner Integration Wpływ na baseline: Niski Powiązane rozdziały: 59.10, 61.1
- SYLION może integrować się z systemami ERP/CRM operatora (Salesforce, SAP, Microsoft Dynamics) jako source/sink danych w kontekście workloadów CRM.
- Model:
- ERP/CRM integracja jest realizowana jako workload operatora — nie jako integracja platformy. Operator deploys adapter CRM w swoim microVM environment. SYLION dostarcza: - Template adapter (connector factory — patrz 59.10). - API access (OAuth-secured) do SYLION metadata (operator info, session data — za zgodą). - Webhook events (session lifecycle) do triggering CRM workflows.
- SYLION nie jest proxy/middleware dla ERP/CRM — odpowiedzialność za integrację leży po stronie operatora.

59.6 Ticketing/ITSM — ServiceNow, Jira

- Status: [R] Rekomendowany Odbiorca: SOC, SRE, Compliance Wpływ na baseline: Średni Powiązane rozdziały: 59.3, 59.10, 52.8
- Integracja z systemami ticketing/ITSM do zarządzania incydentami i zmianami.

ServiceNow:

Adapter servicenow-adapter w Zone 4.

Automatic incident creation: alert SYLION (security, availability) → ServiceNow incident.

Bidirectional sync: status update w ServiceNow → aktualizacja incydentu w SYLION dashboard.

CMDB sync: SYLION components (mikroserwisy, workloady, certyfikaty) → ServiceNow CMDB CI records.

Change management: deployment w SYLION → ServiceNow Change Request (pre-approved for standard changes).

Jira:

Adapter jira-adapter w Zone 4.

Bug tracking: security finding → Jira issue (z severity mapping).

Remediation tracking: Jira issue lifecycle → SYLION compliance dashboard.

Mapowanie pól:

ACL (Anti-Corruption Layer) tłumaczy model incydentu SYLION na model ServiceNow/Jira. Mapowanie konfigurowane per-deployment (YAML config w Vault).

59.7 Integracje audytowe — eksport dowodów

Status: [N] Normatywny Odbiorca: Compliance, Auditor, Legal Wpływ na baseline: Krytyczny Powiązane rozdziały: 58.4, 62.8, 64.11

Eksport dowodów audytowych (evidence export) jest krytyczną integracją dla compliance i postępowań prawnych.

Endpoint:

POST /v2/audit-logs/export — inicjuje asynchroniczny eksport logów audytowych.

Parametry: - `dateRange`: zakres czasowy. - `operatorId`: filtr operatora (obowiązkowy dla operator-scoped export). - `categories`: lista kategorii zdarzeń. - format: JSON, CSV, CEF. - `encryption`: AES-256-GCM z kluczem publicznym odbiorcy (obowiązkowe).

Bezpieczeństwo:

Eksport wymaga uprawnienia `audit:export` i `dual authorization` (Four-Eyes).

Paczka eksportu podpisana cyfrowo (Ed25519) — odbiorca weryfikuje integralność.

Paczka szyfrowana kluczem publicznym odbiorcy (asymmetric encryption) — SYLION nie ma dostępu do plaintext po zaszyfrowaniu.

Każdy eksport logowany w audit log (meta-audit).

Rate limit: max 1 eksport/h per operator.

łańcuch dowodowy (chain of custody):

Paczka eksportu zawiera: - Dane audytowe (logi). - Metadane: zakres, czas eksportu, eksportujący, zatwierdzający. - Hash chain verification data (hashes łańcucha — odbiorca może niezależnie zweryfikować integralność). - Podpis cyfrowy SYLION.

59.8 Integracje komunikacyjne — federacja Matrix, protokół Signal

Status: [N] / [R] Normatywny (Matrix) / Rekomendowany (Signal) Odbiorca: Architekt, Security Architect, Operator Admin Wpływ na baseline: Wysoki Powiązane rozdziały: 65.6, 64.1

Federacja Matrix:

SYLION opiera się na protokole Matrix jako rdzeniu komunikacyjnym (core messaging). Federacja z zewnętrznymi serwerami Matrix jest opcjonalna per-operator i wymaga jawnej konfiguracji.

Reguły federacji: - Domyślnie: federacja wyłączona (closed federation). - Operator może włączyć federację z whitelistą domen (np. federacja między dwoma operatorami SYLION). - Federacja z publicznymi serwerami Matrix (matrix.org): dozwolona za zgodą operatora z ostrzeżeniem o metadata exposure. - E2EE (Megolm/MLS): obowiązkowe dla federowanych konwersacji.

Protokół Signal:

Signal workload jest oznaczony jako [R] (Rekomendowany, nie Normatywny) ze względu na: - Zależność od zewnętrznej infrastruktury (Signal Foundation servers). - Ekspozycja metadanych (numery telefonów, timing) wobec Signal Foundation. - Brak suwerenności — operator nie kontroluje infrastruktury Signal.

Integracja Signal realizowana jako dedykowany workload (signal-bridge) w microVM operatora. Bridge tłumaczy Matrix ↔ Signal. Operator musi zaakceptować ryzyko metadata exposure (informed consent w konfiguracji).

59.9 Integracje partnerskie — API dla certyfikowanych integratorów

Status: [N] Normatywny Odbiorca: Partner Integration, Architekt, Business Development Wpływ na baseline: Wysoki Powiązane rozdziały: 55.8, 59.10, 61.1

Certyfikowani partnerzy (technology partners, deployment partners, compliance partners) mają dostęp do Partner API — podzbioru SYLION API przeznaczonego dla integracji.

Onboarding partnerski:

Partner Application: formularz + NDA + security questionnaire.

Review: Security Team + Business Development.

Provisioning: partner account + API keys + sandbox environment.

Certification: partner implementuje integrację → testy kontraktowe → security review → certyfikacja.

Publication: integracja dostępna w Marketplace (patrz 61.1).

Partner API scope:

Read: operator metadata, session statistics, health status.

Write: webhook registration, integration config.

Forbidden: user data, audit logs, secrets, admin operations.

Sandbox environment:

Każdy partner otrzymuje izolowany sandbox (dedykowane środowisko testowe) z ograniczonymi zasobami. Sandbox nie ma dostępu do produkcji. Dane w sandbox: synthetic (generowane, nie skopiowane z produkcji).

Partner API versioning:

Partner API podlega tym samym zasadom wersjonowania co główne API (patrz 54.1). Dodatkowa gwarancja: sunset period dla Partner API: minimum 12 miesięcy (niezależnie od tier).

59.10 Fabryka connectorów — budowanie nowych konektorów

Status: [R] Rekomendowany Odbiorca: Backend Developer, Integration Engineer Wpływ na baseline: Średni Powiązane rozdziały: 52.8, 59.1–59.9, 60.8

Connector Factory to framework i tooling do budowania nowych adapterów integracyjnych w ustandaryzowany sposób.

Szablon connectora:

Każdy connector jest mikroserwisem deployowanym w Zone 4 (shared services) zgodnym z szablonem:

```
connector-template/ ├── Dockerfile ├── helm/ | └── values.yaml ├── src/ | ├── adapter.go # logika integracji | ├── config.go # konfiguracja (Vault-backed)
| ├── health.go # health check | ├── metrics.go # Prometheus metrics | ├── circuit_breaker.go # Circuit Breaker ├── tests/ | ├── contract_test.go # testy
kontraktowe | ├── integration_test.go # testy integracyjne └── docs/ └── README.md
```

Wymagania connectora:

Circuit Breaker (obowiązkowy).

Health check endpoint /healthz.

Prometheus metrics: request count, latency, error rate.

Structured logging (JSON).

Configuration via Vault (no hardcoded secrets).

mTLS for internal communication.

Contract tests (Pact).

Rate limiting awareness (respect 429 from external system).

Connector lifecycle:

Development → Code review → Security review → Contract test → Integration test (sandbox) → Staging → Production. Connector deployment wymaga zatwierdzenia ARB.

59.11 Adaptery branżowe

Status: [O] Opcjonalny Odbiorca: Architekt, Business Development, Partner Integration Wpływ na baseline: Niski Powiązane rozdziały: 59.10, 61.1, 61.8

Adaptery branżowe to pre-built connectors dla specyficznych branż:

Finanse: integracja z SWIFT (messaging), Bloomberg (market data), regulators (reporting API). Wymaga dodatkowej certyfikacji (PCI DSS, SOX controls).

Administracja publiczna: integracja z ePUAP, krajowe systemy tożsamości (eIDAS), systemy zarządzania dokumentami (EZD). Wymaga certyfikacji CC (Common Criteria) lub krajowej równoważnej.

Healthcare: integracja z HL7 FHIR (health data exchange), DICOM (medical imaging). Wymaga HIPAA compliance / odpowiednik krajowy.

Defence: integracje z NATO communication systems, narodowymi systemami C2 (Command and Control). Wymaga certyfikacji tajemnicy państwowej.

Adaptery branżowe nie są częścią baseline SYLION — realizowane jako osobne produkty lub przez certyfikowanych partnerów branżowych. ## ## Rozdział 60. SDK, CLI i narzędzia deweloperskie

60.1 SDK Java

Status: [R] Rekomendowany Odbiorca: Backend Developer (Java/Kotlin), Partner Integration Wpływ na baseline: Średni Powiązane rozdziały: 53.2, 55.1, 60.8

SDK Java jest generowany automatycznie ze specyfikacji OpenAPI za pomocą OpenAPI Generator (java-okhttp lub java-httpclient jako engine). SDK dystrybuowany jako artefakt Maven (Maven Central lub prywatne repozytorium Nexus).

Architektura SDK:

```
sylicon-sdk-java/ ├── sylicon-sdk-core/ # Wspólne modele, konfiguracja, auth ├── sylicon-sdk-sessions/ # API sesji ├── sylicon-sdk-operators/ # API operatorów
| ├── sylicon-sdk-policies/ # API polityk ├── sylicon-sdk-audit/ # API audytu └── sylicon-sdk-webhooks/ # Obsługa webhooków (weryfikacja podpisów)
```

Wymagania:

Java 17+ (LTS). Kompatybilność z Java 21.

Zero runtime dependencies poza HTTP client (java.net.http lub OkHttp).

Thread-safe: wszystkie klasy klientów immutable i thread-safe.

OAuth 2.0 + PKCE (interactive) i Client Credentials (service) wbudowane w SDK.

mTLS support: konfiguracja TrustStore/KeyStore.

Retry z exponential backoff + jitter (patrz 56.8) wbudowany.

Rate limit handling: automatic retry na 429 z respektowaniem Retry-After.

Pagination: iterator API (lazy loading stron).

Structured logging: SLF4J-compatible.

Telemetry: OpenTelemetry context propagation (trace-id w nagłówkach).

Wersjonowanie:

SDK version = API major version + SDK patch. Np. 2.0.5 — API v2, SDK patch 5. SDK changelog publikowany z każdą wersją.

60.2 SDK .NET

Status: [R] Rekomendowany Odbiorca: Backend Developer (.NET), Partner Integration Wpływ na baseline: Średni Powiązane rozdziały: 53.2, 55.1, 60.8

SDK .NET generowany z OpenAPI (NSwag lub Kiota). Dystrybuowany jako NuGet package.

Wymagania:

.NET 8+ (LTS).

HttpClientFactory integration (dependency injection).

Async/await (Task-based Asynchronous Pattern) — wszystkie operacje asynchroniczne.

IOptions pattern dla konfiguracji.

Polly integration: retry, circuit breaker, timeout (wbudowane polityki SYLION).

mTLS: HttpClientHandler z X509Certificate2.

Logging: Microsoft.Extensions.Logging.

Telemetry: System.Diagnostics.Activity (OpenTelemetry-compatible).

Przykład użycia:

```
services.AddSylonClient(options => { options.BaseUrl = "https://api.sylon.example/v2/"; options.ClientId = "my-service"; options.ClientSecret = vaultSecret;
options.EnableMtls(certPath, keyPath); }); var sessions = await sylonClient.Sessions.ListAsync(operatorId, status: "ACTIVE");
```

60.3 SDK Python

Status: [R] Rekomendowany Odbiorca: Backend Developer (Python), Data Engineer, SOC Automation Wpływ na baseline: Średni Powiązane rozdziały: 53.2, 55.1, 60.8

SDK Python generowany z OpenAPI (openapi-python-client). Dystrybuowany jako PyPI package.

Wymagania:

Python 3.11+.

httpx jako HTTP client (async-native).

Pydantic v2 dla modeli danych (validation, serialization).

Async-first: wszystkie metody async (z sync wrapper dla prostych użyć).

Type hints: 100% coverage (PEP 484, PEP 604).

OAuth 2.0: authlib integration.

mTLS: certyfikaty przez httpx TLS config.

Retry: tenacity library (exponential backoff + jitter).

Context manager: async with SylonClient(...) as client.

Zastosowania specjalne:

SOC automation: skrypty incident response (terminate sessions, export audit, rotate certs).

Data pipeline: eksport metryk i logów do data lake.

Testing: pytest fixtures z mock server (patrz 60.9).

60.4 SDK Go

Status: [N] Normatywny Odbiorca: Backend Developer (Go), Infrastructure Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 53.2, 53.3, 55.1

SDK Go jest podstawowym SDK wewnętrznym SYLION (mikroserwisy SYLION napisane w Go). Generowany z OpenAPI + ręczne rozszerzenia dla gRPC clients.

Wymagania:

Go 1.22+.

net/http standard library (brak zewnętrznych HTTP clients).

gRPC client (google.golang.org/grpc) dla komunikacji wewnętrznej.

Context propagation (context.Context) — obowiązkowe we wszystkich metodach.

Functional options pattern dla konfiguracji.

mTLS: tls.Config z certyfikatami z SPIRE Agent (SDS API).

Retry: custom retry z exponential backoff + jitter (brak ciężkich zależności).

Error handling: structured errors (errors.As/Is), wrapping z kontekstem.

Telemetry: OpenTelemetry SDK (go.opentelemetry.io).

Zero external dependencies poza gRPC i OpenTelemetry (minimalizm).

Struktura:

```
client, err := sylion.NewClient( sylion.WithBaseURL("https://api.sylion.example/v2/"), sylion.WithMTLS(certFile, keyFile, caFile),
sylian.WithOAuth2ClientCredentials(clientID, clientSecret, tokenURL), ) sessions, err := client.Sessions.List(ctx, &sylian.ListSessionsParams{ OperatorID: "op-123",
Status: sylian.SessionStatusActive, })
```

60.5 SDK JavaScript/TypeScript

Status: [R] Rekomendowany Odbiorca: Frontend Developer, Partner Integration, DevTools Wpływ na baseline: Średni Powiązane rozdziały: 53.2, 55.1, 60.8

SDK TypeScript generowany z OpenAPI (openapi-typescript-codegen lub orval). Dystrybuowany jako npm package.

Wymagania:

TypeScript 5.x+ (strict mode).

fetch API (browser + Node.js 18+ native fetch).

Zod schemas dla runtime validation (opcjonalne, generowane ze schematów).

OAuth 2.0 + PKCE (dla browser clients).

Tree-shakeable: modular exports, dead code elimination.

ESM-first (CommonJS jako fallback).

Browser-safe: brak Node.js-specific APIs w core package. Node.js-specific (mTLS, cert loading) w osobnym @sylian/sdk-node.

Podział:

@sylian/sdk-core: typy, modele, konfiguracja.

@sylian/sdk-browser: browser client (PKCE flow, cookie-based refresh).

@sylian/sdk-node: Node.js client (mTLS, Client Credentials).

@sylian/sdk-webhook: webhook verification library (signature checking).

60.6 CLI administracyjne

Status: [N] Normatywny Odbiorca: Operator Admin, SRE, SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 55.1, 66.6, 60.7

Admin CLI (sylian-admin) to narzędzie command-line do zarządzania platformą SYLION.

Architektura:

Język: Go (single binary, cross-platform).

Authentication: OAuth 2.0 Device Authorization Grant → browser login → token stored w OS keyring (macOS Keychain, Windows Credential Manager, Linux secret-service/kwallet).

Output: table (default), JSON (--output json), YAML (--output yaml).

Configuration: ~/.sylian/config.yaml (endpoint, default operator, default output format).

Polecenia:

```
# Operatorzy sylian-admin operator list sylian-admin operator get <operator-id> sylian-admin operator suspend <operator-id> --reason "Security incident"
sylian-admin operator unsuspend <operator-id> --four-eyes-token <token> # Sesje sylian-admin session list --operator <id> --status ACTIVE sylian-admin
session terminate <session-id> --reason "Policy violation" # Polityki sylian-admin policy list sylian-admin policy apply -f policy.yaml sylian-admin policy validate -f
policy.yaml # Certyfikaty sylian-admin cert list --expiring-within 7d sylian-admin cert rotate <cert-id> sylian-admin cert revoke <cert-id> --four-eyes-token
<token> # Audit sylian-admin audit search --since 24h --action "operator.suspend" sylian-admin audit export --since 7d --format json --encrypt-to auditor-
pubkey.pem # Secrets sylian-admin secret rotate <path> --four-eyes-token <token> # Health sylian-admin health check sylian-admin health components
```

Four-Eyes w CLI:

Operacje destrukcyjne wymagają --four-eyes-token. Workflow: 1. Admin A wykonuje: sylian-admin cert revoke abc-123 → system zwraca pending approval request ID. 2. Admin B wykonuje: sylian-admin approve <request-id> → zwraca four-eyes-token. 3. Admin A wykonuje: sylian-admin cert revoke abc-123 --four-eyes-token

<token>.

60.7 CLI deweloperskie

Status: [R] Rekomendowany Odbiorca: Backend Developer, Integration Engineer Wpływ na baseline: Średni Powiązane rozdziały: 60.6, 60.9, 60.10

Developer CLI (syliion-dev) to narzędzie do development workflow.

Polecenia:

```
# Lokalny development syliion-dev init # scaffolding nowego connectora syliion-dev mock start # uruchomienie mock serwera SYLION API syliion-dev mock seed --
scenario basic # załadowanie danych testowych # Kontrakty syliion-dev contract validate -f openapi.yaml syliion-dev contract diff -f openapi.yaml --against
production syliion-dev contract test --pact-dir ./pacts # Protobuf syliion-dev proto lint syliion-dev proto breaking --against main syliion-dev proto generate --lang
go,java,python # Migracje syliion-dev migration create "add_pqc_column" syliion-dev migration validate syliion-dev migration test --db-url postgres://... # Security
syliion-dev security scan --image my-connector:latest syliion-dev security sbom generate --format cyclonedx
```

60.8 Generatory kodu

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps Wpływ na baseline: Wysoki Powiązane rozdziały: 53.2, 53.3, 60.1–60.5

Generatory kodu automatycznie tworzą klienty SDK, server stubs i modele z kontraktów API.

Pipeline generacji:

[OpenAPI Spec] → [Spectral Lint] → [OpenAPI Generator] → [SDK packages] [Proto files] → [buf lint] → [buf generate] → [gRPC stubs per-language]

OpenAPI Generator — konfiguracja SYLION:

Generator uruchamiany w CI (GitHub Actions / GitLab CI) po merge do api-specs repository. Customizacje: - Templates: custom Mustache templates z SYLION-specific extensions (mTLS config, retry policy, Four-Eyes header). - Post-processing: formatowanie kodu (gofmt, black, prettier), linting. - Output: artefakty publikowane do package registries (Maven, NuGet, PyPI, npm) automatycznie.

buf generate — konfiguracja:

buf.gen.yaml definiuje pluginy per-język:

version: v2 plugins: - remote: buf.build/grpc/go out: gen/go - remote: buf.build/grpc/java out: gen/java - remote: buf.build/protocolbuffers/python out: gen/python

Zakaz ręcznych modyfikacji:

Wygenerowany kod nie może być ręcznie modyfikowany. Zmiany wyłącznie przez modyfikację specyfikacji źródłowej lub szablonów generatora. Wygenerowany kod commitowany do dedykowanych repozytoriów z CI verification (regeneracja + diff = puste).

60.9 Mock servers

Status: [R] Rekomendowany Odbiorca: Frontend Developer, Partner Integration, QA Wpływ na baseline: Średni Powiązane rozdziały: 53.2, 60.7, 53.8

Mock server symuluje SYLION API dla development i testowania bez dostępu do produkcji.

Implementacja:

Prism (Stoplight) jako mock server — generuje odpowiedzi na podstawie specyfikacji OpenAPI (examples i schema-based generation). Deployment:

Lokalny: syliion-dev mock start — uruchamia Prism lokalnie.

Shared sandbox: dedykowany mock server dostępny pod <https://mock.sylian.{domain}> dla partnerów.

Scenariusze:

Mock server obsługuje predefined scenarios: - basic: standardowy flow (create operator → create session → terminate). - error: wszystkie endpointy zwracają specyficzne kody błędów. - rate-limited: symulacja throttlingu (429 co N requestów). - four-eyes: symulacja workflow dual authorization. - degraded: losowe opóźnienia i błędy (chaos testing).

Scenariusze konfigurowane przez header X-Mock-Scenario.

Contract verification:

Mock server uruchamiany w CI jako target dla testów kontraktowych konsumenta (Pact provider).

60.10 Toolkity testów kontraktowych

Status: [N] Normatywny Odbiorca: Backend Developer, QA Wpływ na baseline: Wysoki Powiązane rozdziały: 53.8, 54.7, 60.8

SYLION dostarcza gotowe toolkity testów kontraktowych per-język:

@sylian/contract-testing (npm): - Pact JS wrapper z pre-configured SYLION API interactions. - Fixtures z przykładowymi danymi (operators, sessions, policies). - CI integration: npx sylian-contract-test --pact-broker-url ...

sylian-contract-testing (PyPI): - Pact Python wrapper. - pytest plugin: @pytest.mark.sylian_contract.

sylian-contract-testing (Maven): - Pact JVM wrapper. - JUnit 5 extension: @SylianContractTest.

sylian-contract-testing (Go module): - Pact Go wrapper. - testify-compatible assertions.

Każdy toolkit zawiera: - Pre-built provider states (np. „operator exists”, „session active”). - Schema validators (JSON Schema validation wbudowana). - CI/CD integration scripts (GitHub Actions, GitLab CI).

60.11 Helpery IaC

Status: [R] Rekomendowany Odbiorca: DevSecOps, Infrastructure Engineer Wpływ na baseline: Średni Powiązane rozdziały: 69.7, 63.1, 58.1

Infrastructure as Code helpers ułatwiają provisioning infrastruktury SYLION.

Terraform provider (terraform-provider-sylon):

```
resource "sylon_operator" "acme" { name = "ACME Corp" tier = "PRO" max_users = 100 contact_email = "admin@acme.com" } resource "sylon_environment" "acme_prod" { operator_id = sylon_operator.acme.id name = "production" resource_limits = { max_sessions = 50 max_cpu_cores = 32 max_memory_gb = 64 } } resource "sylon_policy" "acme_egress" { operator_id = sylon_operator.acme.id type = "EGRESS" document = file("policies/egress.json") }
```

Helm charts:

Oficjalne Helm charts dla deployment SYLION: - sylon/platform — pełny deployment (all components). - sylon/session-broker — pojedynczy komponent. - sylon/monitoring — stack monitoringu (VictoriaMetrics + Grafana + alerting).

Charts przechowywane w OCI registry (Harbor/GHCR). Podpisane (Helm provenance).

Ansible roles:

Dla deployment on-premises: Ansible roles do provisioningu bare metal / VM: - sylon.base — hardening OS (CIS benchmark). - sylon.vault — deployment Vault cluster. - sylon.kubernetes — bootstrap K8s cluster. - sylon.network — konfiguracja IPsec, firewall rules.

60.12 Biblioteki bezpieczeństwa i referencyjne integracje

Status: [N] Normatywny Odbiorca: Backend Developer, Security Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 55.1, 52.7, 65.1

SYLION dostarcza biblioteki bezpieczeństwa jako reusable components dla mikroservisów i integracji partnerskich.

Biblioteki:

Nazwa	Język	Funkcjonalność
sylon-auth	Go, Java, Python, TS	JWT validation, OAuth token management, scope checking
sylon-mtls	Go, Java	mTLS setup, SPIFFE ID extraction, cert rotation
sylon-webhook-verify	Go, Java, Python, TS	HMAC signature verification, timestamp validation, replay protection
sylon-audit-client	Go, Java, Python	Structured audit log emission, hash chain computation
sylon-crypto	Go, Java	Encryption helpers (AES-256-GCM, Ed25519 sign/verify, PQC hybrid)
sylon-policy-client	Go	OPA client, policy decision caching, fallback handling

Referencyjne integracje:

Repozytorium sylon-reference-integrations zawiera pełne, działające przykłady integracji: - SIEM adapter (Splunk HEC). - ITSM adapter (ServiceNow). - IdP connector (Azure AD OIDC). - Webhook consumer (Node.js). - Custom policy (OPA Rego).

Każda referencyjna integracja zawiera: kod źródłowy, Dockerfile, Helm chart, testy, dokumentację, deployment guide.

Rozdział 61. Marketplace, pluginy i rozszerzalność

61.1 Cel ekosystemu rozszerzeń

Status: [R] Rekomendowany Odbiorca: Product Owner, Architekt, Business Development Wpływ na baseline: Średni Powiązane rozdziały: 59.9, 59.11, 61.2

Ekosystem rozszerzeń SYLION umożliwia partnerom i operatorom rozszerzanie funkcjonalności platformy bez modyfikacji kodu bazowego. Cel: skalowanie wartości platformy przez społeczność partnerów przy zachowaniu bezpieczeństwa i jakości.

Zasady ekosystemu:

Security-first: żadne rozszerzenie nie może osłabić bezpieczeństwa platformy. Izolacja i sandboxing obowiązkowe.

Certification-required: każde rozszerzenie musi przejść proces certyfikacji przed publikacją.

Platform stability: rozszerzenia nie mogą wpływać na stabilność core platform (blast radius isolation).

Operator choice: operator decyduje, które rozszerzenia zainstalować. Brak automatycznych instalacji.

Traceability: każde rozszerzenie logowane w audit trail — kto zainstalował, kiedy, jakie uprawnienia.

Kategorie rozszerzeń:

Connectors: adaptery do zewnętrznych systemów (SIEM, ITSM, IdP, CRM).

Policies: custom policy packs (Rego) dla specyficznych branż/regulacji.

Workflows: automatyzacje (incident response playbooks, compliance workflows).

UI extensions: widżety dashboard (operator panel).

Analytics: custom reports i dashboards.

61.2 Model pluginów — wymagania izolacji, security sandbox

Status: [N] Normatywny Odbiorca: Architekt, Security Architect, Backend Developer Wpływ na baseline: Krytyczny Powiązane rozdziały: 61.3, 61.4, 67.14

Każdy plugin (rozszerzenie) musi być uruchamiany w izolowanym środowisku zapewniającym separation od core platform i od innych pluginów.

Model izolacji:

Pluginsy uruchamiane jako osobne kontenery (lub microVM dla pluginów o wysokim ryzyku) w Zone 4 (shared services). Izolacja:

Network: dedykowany network namespace. Plugin nie ma dostępu do sieci wewnętrznej SYLION. Komunikacja z SYLION wyłącznie przez Plugin API Gateway (dedykowany reverse proxy).

Filesystem: read-only rootfs. Writable volume ograniczony do /data (max 1GB).

Resources: CPU limit (0.5 core), memory limit (512MB), PID limit (100). Quota egzekwowana przez cgroups.

Capabilities: żadne Linux capabilities (no CAP_NET_RAW, no CAP_SYS_ADMIN). Seccomp profile: restrictive (whitelist syscalls).

Secrets: plugin nie ma dostępu do Vault SYLION. Plugin-specific secrets przechowywane w dedykowanym Vault namespace z ograniczonym TTL.

Plugin API:

Plugin komunikuje się z SYLION wyłącznie przez Plugin API — podzbiór REST API z ograniczonym scope: - Read: operator metadata, session statistics (za zgodą operatora). - Write: webhook registration, UI widget registration, custom event emission. - Forbidden: admin operations, user data, secrets, audit logs, policy modification.

61.3 Izolacja rozszerzeń

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 61.2, 61.4, 68.4

Wielowarstwowa izolacja:

Warstwa	Mechanizm	Cel
Network	Network Policy (Kubernetes) + Plugin API Gateway	Brak lateral movement
Compute	Container (domyślnie) lub microVM (high-risk)	Izolacja procesów
Storage	Dedicated PV per plugin, encrypted, quota-limited	Brak dostępu do danych innych pluginów
Identity	Dedykowany service account per plugin (SPIFFE ID)	Least privilege
Egress	Egress policy: deny-all default, whitelist per-plugin	Zapobieganie exfiltration
Monitoring	eBPF-based runtime monitoring (Tetragon)	Wykrywanie anomalii

Eskalacja izolacji:

Jeśli plugin wymaga wyższych uprawnień (np. dostęp do network stack, custom kernel modules) — uruchamiany w microVM (Firecracker) zamiast kontenera. Decyzja o eskalacji podejmowana w procesie certyfikacji (61.5).

Blast radius:

Kompromitacja pluginu nie może wpłynąć na: - Core platform (session broker, policy engine, audit). - Inne pluginy. - Dane operatora (poza danymi jawnie udostępnionymi pluginowi).

Blast radius ograniczony do: danych pluginu (max 1GB), zasobów pluginu (0.5 core, 512MB), network scope pluginu (Plugin API only).

61.4 Polityki bezpieczeństwa pluginów

Status: [N] Normatywny Odbiorca: Security Architect, DevSecOps, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 61.2, 61.3, 61.5

Manifest pluginu:

Każdy plugin deklaruje wymagane uprawnienia w manifeście (plugin.yaml):

apiVersion: sylion.io/v1 kind: Plugin metadata: name: splunk-connector version: 1.2.0 vendor: Acme Security Ltd signature: <Ed25519 signature> spec: permissions: - resource: audit-events actions: [read, subscribe] - resource: operator-metadata actions: [read] egress: - host: "*.splunkcloud.com" port: 8088 protocol: https resources: cpu: "0.25" memory: "256Mi" storage: "500Mi" isolation: container # or microvm

Policy enforcement:

Manifest jest weryfikowany przy instalacji. Uprawnienia przekraczające deklarowane → instalacja zablokowana.

Runtime enforcement: OPA policy weryfikuje, czy plugin API requests odpowiadają deklarowanym permissions.

Egress enforcement: network policy dopuszcza wyłącznie zadeklarowane hosty. Próba połączenia z innym hostem → blokada + alert.

Resource enforcement: cgroup limits. Przekroczenie → throttling (CPU) lub OOMKill (memory) → restart pluginu.

Limity:

Max 20 pluginów per operator.

Max 5 pluginów per environment.

Łączne zasoby pluginów: max 20% zasobów environment.

61.5 Proces certyfikacji rozszerzeń

Status: [N] Normatywny Odbiorca: Partner Integration, Security Team, QA Wpływ na baseline: Krytyczny Powiązane rozdziały: 61.4, 61.6, 69.1

Każde rozszerzenie musi przejść wieloetapowy proces certyfikacji przed publikacją w Marketplace.

Etapy:

Submission: vendor przesyła: kod źródłowy (lub obraz kontenera), manifest, dokumentację, SBOM.

Automated scan:

SAST (static analysis) — brak known vulnerabilities, brak hardcoded secrets.

SCA (dependency scan) — brak CVE >MEDIUM bez mitygacji.

SBOM verification — kompletność, brak nieautoryzowanych dependencies.

Container image scan — brak malware, minimalna base image.

Manifest validation — uprawnienia adekwatne do deklarowanej funkcjonalności.

Security review: ręczny przegląd przez SYLION Security Team:

Analiza uprawnień — czy plugin potrzebuje tego co deklaruje.

Analiza egress — czy deklarowane hosty są uzasadnione.

Analiza kodu — brak backdoorów, brak data exfiltration.

Functional testing: plugin działa zgodnie z dokumentacją w sandbox environment.

Performance testing: plugin nie degraduje platformy (resource consumption w limitach).

Approval / Rejection: Security Team + Product Team decision. Rejection z feedback.

Re-certyfikacja:

Każda nowa wersja pluginu: automated scan (etap 2). Security review (etap 3) jeśli zmiany w uprawnieniach lub egress.

Periodic re-certification: co 12 miesięcy (pełny cykl).

Emergency de-certification: jeśli wykryto vulnerability w runtime → plugin natychmiast usuwany z Marketplace + alert do operatorów.

61.6 Podpisywanie i dystrybucja

Status: [N] Normatywny Odbiorca: DevSecOps, Partner Integration Wpływ na baseline: Krytyczny Powiązane rozdziały: 61.5, 69.4, 69.5

Podpisywanie:

Każdy certyfikowany plugin jest podpisywany przez SYLION: 1. Vendor podpisuje artefakt swoim kluczem (Ed25519) — proof of origin. 2. SYLION podpisuje artefakt po certyfikacji kluczem SYLION Marketplace (Ed25519) — proof of certification. 3. Dual signature weryfikowana przy instalacji. Brak jednego podpisu → instalacja zablokowana.

Klucze publiczne vendorów publikowane w Marketplace. Klucz publiczny SYLION Marketplace dystrybuowany z platformą (embedded w binary).

Dystrybucja:

Plugin images dystrybuowane przez OCI registry (Harbor/GHCR) z signature verification (cosign/Sigstore). Pull wyłącznie z autoryzowanego registry — operator nie może zainstalować pluginu z zewnętrznego source.

Integrity verification:

Przy instalacji: 1. Pobranie obrazu z OCI registry. 2. Weryfikacja cosign signature (Sigstore). 3. Weryfikacja SYLION Marketplace signature (Ed25519). 4. Weryfikacja SBOM (obecny, kompletny). 5. Porównanie manifest hash z zarejestrowanym w Marketplace.

Brak weryfikacji → instalacja zablokowana.

61.7 Governance Marketplace

Status: [N] Normatywny Odbiorca: Product Owner, Legal, Business Development Wpływ na baseline: Wysoki Powiązane rozdziały: 61.5, 61.6, 61.9

Zasady governance:

Kuratela: SYLION utrzymuje kuratorski model (nie open marketplace). Każdy plugin wymaga certyfikacji.

Jakość: minimum rating 3/5 (po 30 dniach) lub plugin jest przeglądany i potencjalnie usuwany.

Security SLA: vendor musi naprawić vulnerability CRITICAL w 72h, HIGH w 7 dni. Brak naprawy → de-certification.

Compatibility: plugin musi być kompatybilny z aktualną i poprzednią major version API SYLION.

Support: vendor musi zapewnić support channel dla operatorów korzystających z pluginu.

Privacy: plugin nie może zbierać danych operatora/użytkownika poza zadeklarowanym w manifeście scope.

Removal:

Plugin może być usunięty z Marketplace: - Na żądanie vendora. - Za naruszenie governance (security SLA, privacy, quality). - Za nieaktywność vendora (brak update >12 miesięcy i vulnerabilities unpatched).

Przy usunięciu: operator notyfikowany, plugin działa jeszcze 30 dni (grace period), potem automatycznie dezaktywowany.

61.8 Kategorie partnerów — technologia, deployment, compliance

Status: [R] Rekomendowany Odbiorca: Business Development, Partner Integration Wpływ na baseline: Niski Powiązane rozdziały: 59.9, 61.1, 59.11

Technology Partners:

Firmy dostarczające rozszerzenia techniczne (connectors, policy packs, analytics tools). Wymagania: certyfikacja pluginu, NDA, security questionnaire, support SLA.

Deployment Partners:

Firmy wdrażające SYLION u klientów (consulting, integration, customization). Wymagania: szkolenie certyfikacyjne (SYLION Deployment Certification), demo deployment, support capability.

Compliance Partners:

Firmy specjalizujące się w compliance i audycie (regulatory advisors, auditors). Wymagania: relevant certifications (ISO 27001 Lead Auditor, CISA), NDA, access to compliance documentation.

Tiering partnerski:

Registered: dostęp do sandbox, dokumentacji, community.

Certified: przejście certyfikacji, listing w Marketplace, co-marketing.

Premier: głęboka integracja, early access do nowych API, dedykowany support.

61.9 Model revenue sharing

Status: [O] Opcjonalny Odbiorca: Business Development, Finance, Legal Wpływ na baseline: Niski Powiązane rozdziały: 61.7, 59.4

Dla płatnych pluginów w Marketplace:

Revenue split: 70% vendor / 30% SYLION (standard). 80/20 dla Premier partners.

Pricing: vendor ustala cenę. Minimum: 10 EUR/miesiąc. SYLION zastrzega prawo veto na cenę.

Billing: SYLION pobiera opłatę od operatora (zintegrowane z subskrypcją). Rozliczenie z vendorem: monthly.

Free tier: vendor może oferować wersję free (z ograniczoną funkcjonalnością). SYLION nie pobiera prowizji od free plugins.

61.10 Ryzyka ekosystemu pluginów

Status: [N] Normatywny Odbiorca: Security Architect, Product Owner, CISO Wpływ na baseline: Wysoki Powiązane rozdziały: 61.2, 61.4, 67.8

Zidentyfikowane ryzyka:

Ryzyko	Prawdopodobieństwo	Wpływ	Mitygacja
Malicious plugin (backdoor, exfiltration)	Średnie	Krytyczny	Certyfikacja, code review, runtime monitoring
Supply chain compromise (plugin dependency)	Wysokie	Wysoki	SBOM, SCA, dependency pinning
Privilege escalation (plugin exploits API)	Niskie	Krytyczny	OPA enforcement, minimal API surface
Resource exhaustion (DoS by plugin)	Średnie	Wysoki	cgroup limits, auto-kill, quota
Data leak (plugin exfiltrates operator data)	Średnie	Krytyczny	Egress policy, audit logging, minimal data access
Vendor abandonment (unsupported plugin)	Wysokie	Średni	Re-certification policy, 12-month activity check
Compatibility break (SYLION update breaks plugin)	Średnie	Średni	Contract tests, sunset policy, compatibility matrix

Akceptacja ryzyka:

Decyzja o uruchomieniu ekosystemu pluginów musi być zatwierdzona przez CISO z jawną akceptacją ryzyk rezydualnych. Każdy operator instalujący plugin akceptuje dodatkowe ryzyko (informed consent w UI). # CZĘŚĆ VII — BEZPIECZEŃSTWO ARCHITEKTURY I OBRONA SYSTEMU

CZĘŚĆ VII — BEZPIECZEŃSTWO ARCHITEKTURY I OBRONA SYSTEMU

Rozdział 62. Secure by design

62.1 Zasady podstawowe — właściwości bezpieczeństwa niezależne od implementacji

Status: [N] Normatywny Odbiorca: Architekt, Security Architect, CISO, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.2–62.10, 63.1, 64.1

SYLION jest projektowany według zasady secure-by-design — właściwości bezpieczeństwa są fundamentem architektury, nie nakładką. Poniższe właściwości muszą być zachowane niezależnie od wybranej implementacji, cloud providera czy trybu deployment.

Właściwości invariantne:

Confidentiality in transit: Każdy bajt danych przemieszczający się między komponentami SYLION jest szyfrowany (IPsec IKEv2 / mTLS). Brak plaintext na wire — bez wyjątków.

Confidentiality at rest: Wszystkie dane persystowane są szyfrowane (AES-256-GCM minimum). Klucze zarządzane przez HSM/Vault.

Authentication required: Każdy request (human, service, system) musi być uwierzytelniony. Brak anonimowego dostępu do jakiegokolwiek endpointu.

Authorization enforced: Każdy request jest autoryzowany — policy engine (OPA) podejmuje jawną decyzję allow/deny. Brak implicit allow.

Auditability: Każda operacja mutująca jest logowana w tamper-evident audit log (hash chains + WORM). Logi nie mogą być modyfikowane ani usunięte.

Isolation: Dane i workloady operatora A są niewidoczne i niedostępne dla operatora B. Izolacja egzekwowana na wielu warstwach (network, compute, storage, application).

Resilience: Kompromitacja jednego komponentu nie prowadzi do kompromitacji całego systemu. Blast radius ograniczony by-design.

Verifiability: Integralność systemu jest weryfikowalna — attestation (SEV-SNP/TDX), signed artifacts, hash chains, SBOM.

Minimalism: System ekspozuje minimalną powierzchnię ataku — każdy port, serwis, biblioteka musi mieć uzasadnienie.

Replaceability: Żaden komponent nie jest nieodwracalny — rebuild-first approach zamiast patching (patrz 62.7).

Naruszenie którejkolwiek z powyższych właściwości stanowi defekt bezpieczeństwa P0 i wymaga natychmiastowej naprawy.

62.2 Least privilege — implementacja per-zone, per-workload, per-role

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect, Backend Developer Wpływ na baseline: Krytyczny Powiązane rozdziały: 55.7, 63.1, 66.1

Zasada najmniejszych uprawnień (Least Privilege) jest egzekwowana na każdym poziomie architektury SYLION.

Per-zone:

Każda strefa (Zone 0–5) posiada jawnie zdefiniowany zbiór uprawnień: - Zone 0 (endpoint): brak uprawnień do infrastruktury. Dostęp wyłącznie do session broker (Zone 2). - Zone 1 (access): terminacja TLS, rate limiting, basic auth — brak dostępu do danych. - Zone 2 (G1/G2): brokering sesji — brak dostępu do treści komunikacji. - Zone 3 (workloads): dostęp do danych operatora — wyłącznie w kontekście sesji i za zgodą polityki. - Zone 4 (shared services): dostęp do usług współdzielonych — brak dostępu do danych operatorów. - Zone 5 (management): zarządzanie platformą — dostęp do konfiguracji, nie do danych operatorów.

Per-workload:

Każdy microVM/kontener posiada: - Dedykowany service account (SPIFFE ID) z minimalnymi uprawnieniami. - Network policy: deny-all default, explicit allow do wymaganych serwisów. - Filesystem: read-only rootfs, writable wyłącznie dedykowane volume. - Capabilities: żadne (no CAP_NET_RAW, no CAP_SYS_ADMIN). Seccomp: restrictive whitelist. - Vault policy: dostęp wyłącznie do ścieżek wymaganych przez workload.

Per-role:

Rola	Uprawnienia	Zabronione
Operator Admin	Zarządzanie operatorem, environments, użytkownikami	Dostęp do innych operatorów, management plane
SOC Analyst	Read audit logs, read security events, investigate incidents	Modify policies, manage operators, access secrets
SOC Responder	+ terminate sessions, isolate workloads, trigger emergency rotation	Delete operators, modify platform config
Platform Admin	Manage platform config, deploy updates	Read operator data, access user sessions
Developer	Deploy to staging, read API docs, run tests	Access production, modify policies, read audit

Rola jest przypisywana użytkownikowi per-operator (user może mieć różne role w różnych operatorach). Eskalacja roli (temporary elevation) wymaga dual authorization i jest automatycznie cofana po 4h.

62.3 Segregation of duties — admin vs operator vs SOC vs developer

Status: [N] Normatywny Odbiorca: CISO, Security Architect, HR Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.2, 64.5, 66.6

Segregacja obowiązków zapewnia, że żadna pojedyncza osoba nie posiada wystarczających uprawnień do samodzielnego naruszenia bezpieczeństwa systemu.

Matryca segregacji:

Operacja	Wymaga roli	Wymaga drugiej roli (Four-Eyes)
Tworzenie operatora	Platform Admin	—
Suspendowanie operatora	Platform Admin	Platform Admin (inny)

Usunięcie operatora	Platform Admin	Platform Admin (inny) + CISO approval
Modyfikacja polityki globalnej	Policy Admin	Security Architect
Rotacja root CA	Platform Admin	CISO + Security Architect
Eksport audit logów	Compliance Officer	Compliance Officer (inny)
Emergency session kill-all	SOC Responder	SOC Manager
Deploy production	DevOps	Security approval (automated gate)
Access break-glass secret	Platform Admin	CISO + physical presence verification

Zasada: Nikt nie posiada uprawnień do jednoczesnego: (a) modyfikacji kodu, (b) deployu do produkcji, (c) zarządzania secrets, (d) czyszczenia audit logs. Te cztery kompetencje muszą być rozdzielone między minimum 3 osoby/role.

Wyjątek break-glass:

W sytuacji kryzysowej (niedostępność wymaganych osób) — procedura break-glass (patrz 66.6). Break-glass: jednorazowe credentials z pełnym uprawnieniem, ale z:

- Pełnym logowaniem (każda operacja na osobnym kanale audytowym).
- Automatycznym powiadomieniem CISO.
- Obowiązkowym post-incident review w ciągu 24h.
- Automatycznym wygaśnięciem po 2h.

62.4 Deny by default — sieć, IAM, egress

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect, Network Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 63.1, 63.9, 67.10

Zasada deny-by-default oznacza, że każdy dostęp (sieciowy, aplikacyjny, danych) jest domyślnie zablokowany i musi być jawnie dozwolony.

Default-deny network:

Kubernetes NetworkPolicy: default deny ingress + egress dla każdego namespace.

Firewall (iptables/nftables): DROP jako default policy. Explicit ACCEPT rules per-flow.

Inter-zone: brak domyślnej komunikacji. Każdy dozwolony flow udokumentowany w macierzy (patrz 63.9).

Egress: deny-all default. Dozwolone wyłącznie: DNS (CoreDNS internal), zdefiniowane external endpoints (per-service whitelist).

Default-deny IAM:

OPA default decision: deny. Każde allow wymaga explicit rule.

Vault policy: deny-all default. Explicit grants per-path, per-capability (read, create, update, delete, list).

Kubernetes RBAC: no default ClusterRoleBinding. Service accounts z minimalnymi rolami.

Default-deny egress:

Egress policy jest krytyczna dla zapobiegania exfiltration: - Workloady operatorów: brak dostępu do internetu (default). Operator może whitelistować domeny (per-environment, za zgodą administratora). - Mikroserwisy SYLION: egress wyłącznie do zdefiniowanych zależności (bazy danych, Vault, event broker, external integrations). - CDR engine: egress zablokowany całkowicie (no network access — files processed in-memory).

62.5 Defense in depth — analiza warstw per-zone

Status: [N] Normatywny Odbiorca: Security Architect, Architekt, CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 63.1–63.6, 64.1, 67.14

Defense in depth oznacza, że bezpieczeństwo nie polega na jednej kontrolce — każda strefa posiada wiele warstw obrony.

Zone 0 (Endpoint):

Warstwa	Kontrolka
Hardware	TPM 2.0 (attestation), Secure Boot
OS	Hardened OS (CIS L2), full-disk encryption
Network	IPsec IKEv2 tunnel do Zone 1
Application	Thin client — minimal attack surface
Authentication	FIDO2/WebAuthn (phishing-resistant)
Data	Brak danych lokalnych (zero local storage)

Zone 1 (Access):

Warstwa	Kontrolka
Network	DDoS protection (volumetric + application)
TLS	Certificate pinning, TLS 1.3 only
WAF	OWASP CRS, custom rules
Rate limiting	Per-client, per-endpoint (patrz 56.1)
Authentication	JWT validation, mTLS verification

Zone 2 (G1/G2 Gateway):

Warstwa	Kontrolka
---------	-----------

Network	IPsec between G1/G2, microsegmentation
Application	Session broker (brokered access, no direct connections)
Isolation	G1/G2 split — confidentiality vs availability separation
Monitoring	Real-time session monitoring, anomaly detection

Zone 3 (Workloads):

Warstwa	Kontrolka
Compute	Firecracker microVM, SEV-SNP/TDX memory encryption
Network	Microsegmentation (per-operator network namespace)
Runtime	eBPF monitoring (Tetragon), seccomp, AppArmor
Data	Per-operator encryption keys, RLS
CDR	Content Disarm & Reconstruct pipeline

Zone 4 (Shared Services):

Warstwa	Kontrolka
Network	Internal-only, no external access
Authentication	mTLS (SPIFFE/SVID)
Data	Encryption at-rest, WORM for audit
Monitoring	Centralized logging, alerting

Zone 5 (Management):

Warstwa	Kontrolka
Network	Most restricted — access from dedicated admin network only
Authentication	FIDO2 + step-up + Four-Eyes
Secrets	Vault (HSM-backed)
Audit	Complete audit trail, tamper-evident
Physical	HSM for root keys (FIPS 140-3 L3)

62.6 Redukcja blast radius — izolacja ograniczająca szkody per-typ incydentu

Status: [N] Normatywny Odbiorca: Security Architect, Architekt, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.5, 64.1, 67.14

Analiza blast radius per-incident:

Incident	Blast radius bez izolacji	Blast radius SYLION	Mechanizm
Kompromitacja terminala	Dostęp do platformy	Sesja jednego użytkownika	Thin client, brak lokalnych danych
Kompromitacja workloadu	Lateral movement po sieci	Dane jednego operatora w jednym env	MicroVM isolation, per-operator network
Kompromitacja session broker	Wszystkie sesje	Sesje na jednym nodzie brokera	Horizontal scaling, per-node isolation
Kompromitacja bazy danych	Wszystkie dane operatorów	Dane jednego bounded context	Database-per-service, RLS, encryption
Kompromitacja Vault	Wszystkie sekrety	Sekrety jednego namespace	Vault namespaces per-zone
Kompromitacja CI/CD	Supply chain — cały system	Artefakty jednego pipeline	Segregation of CI/CD, signing, SLSA
Wyciek klucza API partnera	Pelen dostęp API	Read-only, IP-limited, operator-scoped	Scope limitation, IP allowlist

Design patterns redukcji blast radius:

Database-per-service: kompromitacja jednej bazy nie daje dostępu do innych.

MicroVM per-operator: kompromitacja workloadu operatora A nie daje dostępu do operatora B.

Network microsegmentation: lateral movement zablokowane by default.

Short-lived credentials: kompromitacja tokenu — max 15 min okno.

Vault namespaces: kompromitacja secrets jednej strefy nie daje dostępu do innych.

Rebuild-first: zamiast patchować skompromitowany system — destroy i rebuild (patrz 62.7).

62.7 Rebuild-first — dlaczego patching jest anty-wzorcem w SYLION, wyjątki

Status: [N] Normatywny Odbiorca: SRE, DevSecOps, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.6, 68.1, 69.6

W tradycyjnych systemach patching jest standardową metodą naprawy vulnerabilities. W SYLION podejście rebuild-first zastępuje patching wszędzie tam, gdzie to możliwe.

Dlaczego rebuild > patch:

Pewność stanu: rebuild z podpisanego obrazu gwarantuje znany, weryfikowalny stan systemu. Patch modyfikuje istniejący stan — nie ma pewności, że system po patchu jest identyczny z zamierzonym.

Eliminacja persistence: jeśli atakujący zainstalował backdoor, rebuild go usuwa. Patch nie gwarantuje usunięcia persistencji.

Atomowość: rebuild jest atomowy — albo nowy obraz działa, albo rollback do poprzedniego. Patch może zawieść w połowie i zostawić system w nieokreślonym stanie.

Testability: nowy obraz jest testowany w pipeline CI/CD przed deploymentem. Patch w runtime jest trudniejszy do testowania.

Auditability: każdy rebuild to nowy artefakt z SBOM i podpisem. Łatwiejszy audit.

Implementacja:

Infrastruktura: immutable infrastructure. Serwery/kontenery/VM nie są patchowane in-place — nowe obrazy budowane, testowane, deployowane (blue-green / rolling).

MicroVM: workload rebuild = nowy obraz Firecracker, nowa instancja. Czas rebuild: <60s.

Kontenery: nowy obraz kontenera, rolling deployment. Czas: <5min.

OS nodów: nowy obraz OS (Flatcar Linux / Talos / RHCOS) deployowany przez node rollout. Czas: <15min per-node.

Wyjątki (gdy rebuild nie jest możliwy):

Bazy danych: nie można zrobić rebuild bazy z danymi. Patching PostgreSQL: paczka serwisowa z testami, rolling upgrade (primary → replica promote → patch old primary).

Vault cluster: rolling upgrade (one node at a time). Backup + snapshot przed upgrade.

Stateful workloady z danymi użytkownika: migrate data → rebuild → restore.

W wyjątkach: patch musi przejść testy w staging, ma zatwierdzenie dual authorization, jest logowany w audit log.

62.8 Tamper-evident operations — hash chains, signed audit logs, attestation

Status: [N] Normatywny Odbiorca: Security Architect, Compliance, Auditor Wpływ na baseline: Krytyczny Powiązane rozdziały: 58.4, 59.7, 64.11

Operacje w SYLION muszą być tamper-evident — każda próba manipulacji musi być wykrywalna.

Hash chains (audit logs):

Mechanizm opisany w 58.4. Uzupełnienie: - Hash chain jest per-operator (oddzielny łańcuch dla każdego operatora) + per-zone (oddzielny łańcuch per-strefa). - Cross-chain verification: hash chain operatora zawiera periodic checkpoint hash chain strefy (merkle proof). - External timestamping: hash root co 1h publikowany do zewnętrznego timestamping service (RFC 3161) lub blockchain-based (Ethereum, opcjonalne). Zapewnia niezależną weryfikację czasu.

Signed audit logs:

Każdy wpis logu audytowego podpisany kluczem Ed25519 serwisu generującego log. Klucz publiczny serwisu dostępny w trust registry. Weryfikator (auditor) może niezależnie potwierdzić, że log został wygenerowany przez autoryzowany serwis.

Attestation (hardware-backed):

SEV-SNP attestation: przed uruchomieniem workloadu, host attestuje mikroVM (measurement of guest firmware + kernel). Attestation report podpisany przez AMD PSP. Weryfikowany przez SYLION attestation service (porównanie z expected measurements).

TDX attestation: analogiczny mechanizm (Intel TDX Quote).

TPM attestation (endpoint): thin client attestuje stan systemu (Secure Boot measurements). Weryfikowany przy nawiązywaniu sesji.

Uwaga (defense-in-depth, nie absolutna ochrona):

AMD SEV-SNP, mimo że jest wartościową warstwą obrony, nie stanowi absolutnej gwarancji — znane podatności (CVE-2024-56161, atak „Battering RAM” KU Leuven) oraz 49 CVE w historii wobec 9 CVE TDX wskazują na konieczność traktowania TEE jako jednej z wielu warstw, nie jedyne go mechanizmu ochrony. SYLION stosuje SEV-SNP/TDX jako defense-in-depth, zawsze w połączeniu z izolacją sieciową, RLS, encryption i monitoringiem runtime.

62.9 Data minimization — jakie dane są zbierane, dlaczego, limity retencji

Status: [N] Normatywny Odbiorca: Compliance, DPO, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 58.4, 64.11, 62.8

SYLION stosuje zasadę minimalizacji danych: zbierane są wyłącznie dane niezbędne do świadczenia usługi i zapewnienia bezpieczeństwa.

Dane zbierane:

Kategoria	Dane	Cel	Retencja
Tożsamość operatora	Nazwa, email kontaktowy, tier	Zarządzanie kontem	Czas trwania konta + 30 dni
Tożsamość użytkownika	External ID, rola, mapowanie IdP	Uwierzytelnianie	Czas trwania konta
Sesje	ID, typ, czas rozpoczęcia/zakończenia, IP (hashowane)	Monitoring, audit	Per-tier retencja
Workloady	ID, typ, image hash, host node, zasoby	Orchestration	Czas trwania + 30 dni
Audit logs	Actor, action, resource, result, timestamp	Compliance, forensics	Per-tier (12–60 mies.)
Metryki	Latency, throughput, error rate (bez PII)	Monitoring, SLA	15 dni raw, 365 dni aggregated

Dane NIE zbierane:

Treść komunikacji (wiadomości, pliki, rozmowy) — E2EE, SYLION nie ma dostępu.

Hasła (przechowywany wyłącznie hash bcrypt/argon2).

Dane biometryczne (FIDO2 challenge-response, bez raw biometrics).

Lokalizacja użytkownika (IP hashowane, brak GPS/geolocation tracking).

Browsing history, activity logs poza SYLION platform.

Retencja:

Automatic deletion po upływie retencji. Brak manual override (dane nie mogą być przechowywane dłużej niż polityka, nawet na żądanie operatora). Wyjątek: legal hold — jeśli obowiązuje nakaz sądowy, retencja zostaje zamrożona dla wskazanych danych do momentu zniesienia nakazu. Legal hold logowany w audit.

Right to erasure:

Operator może żądać usunięcia swoich danych (GDPR Art. 17). Proces: dezaktywacja konta → 30-dniowy grace period → fizyczne usunięcie wszystkich danych operatora (cascade) → weryfikacja usunięcia → potwierdzenie.

62.10 Listy kontrolne bezpieczeństwa per warstwa — hardening per-zone

Status: [N] Normatywny Odbiorca: DevSecOps, SRE, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.1–62.9, 63.1, 68.2

Zone 0 — Endpoint Hardening Checklist:

- ☐ Secure Boot enabled
- ☐ TPM 2.0 attestation configured
- ☐ Full-disk encryption (LUKS/BitLocker)
- ☐ Thin client — no local data storage
- ☐ IPsec IKEv2 tunnel configured
- ☐ FIDO2/WebAuthn as primary authenticator
- ☐ Auto-wipe after N failed attempts (configurable)
- ☐ Screen lock timeout ≤5 min
- ☐ USB storage blocked (device policy)
- ☐ Camera/microphone hardware kill switch (STATE)

Zone 1 — Access Hardening Checklist:

- ☐ DDoS protection enabled (L3/L4 + L7)
- ☐ TLS 1.3 only (no TLS 1.2 fallback)
- ☐ WAF enabled (OWASP CRS 4.x)
- ☐ Rate limiting per-client, per-endpoint
- ☐ Certificate pinning configured
- ☐ CORS restrictive (no wildcard origins)
- ☐ Security headers (HSTS, CSP, X-Frame-Options)
- ☐ API Gateway health check active
- ☐ Log all requests to audit pipeline

Zone 2 — G1/G2 Gateway Hardening Checklist:

- ☐ G1/G2 split deployed (separate processes/VMs)
- ☐ IPsec between G1 and G2
- ☐ Session broker — no direct client-to-workload connections
- ☐ Blind broker validation for audio/video (SFrame)
- ☐ Guacamole patched / mitigated (CVE-2024-35164) — marked [E]
- ☐ Session timeout enforced
- ☐ Anomaly detection on session patterns

Zone 3 — Workload Hardening Checklist:

- ☐ Firecracker microVM for operator workloads
- ☐ SEV-SNP / TDX enabled (where available)
- ☐ Network namespace per-operator
- ☐ NetworkPolicy deny-all default
- ☐ Read-only rootfs

- ☐ No privileged containers
- ☐ Seccomp profile: restrictive
- ☐ AppArmor profile: enforced
- ☐ eBPF runtime monitoring active (Tetragon)
- ☐ CDR pipeline active for all file ingress
- ☐ RLS (Row-Level Security) on all operator data

Zone 4 — Shared Services Hardening Checklist:

- ☐ Internal-only network (no external ingress)
- ☐ mTLS between all services
- ☐ Vault: auto-unseal, audit enabled, HA
- ☐ PostgreSQL: TLS, scram-sha-256, pgAudit
- ☐ Redis: TLS, AUTH, no KEYS command
- ☐ Event broker: TLS, ACL, topic restriction
- ☐ Search index: RBAC, document-level security

Zone 5 — Management Hardening Checklist:

- ☐ Access from dedicated admin network only
- ☐ FIDO2 + step-up authentication required
- ☐ Four-Eyes for all destructive operations
- ☐ Vault: HSM-backed root keys
- ☐ CI/CD: ephemeral runners, no persistent credentials
- ☐ Git: signed commits, protected branches
- ☐ Backup encryption verified
- ☐ Disaster recovery tested quarterly

Rozdział 63. Segmentacja sieci i izolacja

Alternatywnie: Keeper Connection Manager (FedRAMP High, stworzony przez twórców Apache Guacamole) lub Zscaler PRA (Privileged Remote Access) jako komercyjne alternatywy z certyfikacjami enterprise. Segmentacja sieci i strefy zaufania

63.1 Zone 0 — Endpoint

Status: [N] Normatywny Odbiorca: Security Architect, Network Engineer, Endpoint Admin Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.2, 62.10, 64.4

Zone 0 obejmuje urządzenia końcowe użytkowników: laptopy z thin klientem, urządzenia mobilne oraz opcjonalnie dedykowane terminale SYLION (tier STATE).

Charakterystyka bezpieczeństwa:

Zone 0 jest najbardziej narażona na kompromitację — fizyczny dostęp atakującego jest realistyczny (kradzież, konfiskata, social engineering). Projektowana z założeniem: „terminal jest potencjalnie skompromitowany — system musi być odporny.”

Kontrolki:

Zero Trust endpoint: terminal nie jest zaufany. Każda sesja wymaga pełnego uwierzytelnienia (FIDO2). Brak session persistence między restartami (no remember-me).

Thin client architecture: terminal nie przechowuje danych. Rendering odbywa się server-side (pixel streaming). Po zakończeniu sesji — brak artefaktów na urządzeniu.

IPsec IKEv2: tunel IPsec z IKEv2 od terminala do Zone 1 (access layer). Certyfikat urządzenia + credential użytkownika. PFS (Perfect Forward Secrecy) obowiązkowe.

Attestation: TPM 2.0 attestation przy nawiązywaniu sesji — weryfikacja Secure Boot chain, integralności OS. Brak attestation → sesja odrzucona (dla tier STATE).

Device policy: MDM-enforced (Mobile Device Management): szyfrowanie dysku, ekran blokady, zakaz USB storage, whitelist aplikacji.

Duress PIN: opcjonalny (tier STATE) — specjalny PIN sygnalizujący przymus. Aktywacja wyzwala cichą procedurę: pozorne logowanie z ograniczonymi/fałszywymi danymi + alert do SOC.

Komunikacja dozwolona:

Zone 0 → Zone 1 (access): IPsec IKEv2 tunnel. Brak bezpośredniej komunikacji Zone 0 ↔ Zone 2/3/4/5.

63.2 Zone 1 — Access

Status: [N] Normatywny Odbiorca: Network Engineer, Security Architect, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 52.8, 56.1, 62.10

Zone 1 jest warstwą dostępu — pierwszym punktem kontaktu z infrastrukturą SYLION. Odpowiada za terminację tuneli IPsec, uwierzytelnianie, routing i ochronę przed atakami na peryferiach.

Komponenty:

IPsec Gateway: terminacja tuneli IKEv2 z Zone 0.

API Gateway: terminacja HTTPS, JWT validation, mTLS verification, rate limiting, WAF.

Load Balancer: L4 (TCP) + L7 (HTTP/2) load balancing do Zone 2.

DDoS Protection: volumetric (L3/L4) + application layer (L7) — CDN-based lub dedicated appliance.

Kontrolki:

TLS 1.3 only: brak TLS 1.2 fallback. Cipher suites: TLS_AES_256_GCM_SHA384, TLS_CHACHA20_POLY1305_SHA256.

Certificate management: certyfikaty zarządzane przez Vault PKI. Auto-rotation (90-day cycle).

WAF: OWASP CRS 4.x. Custom rules per-deployment. False positive tuning w sandbox.

Rate limiting: multi-level (patrz 56.1). Token bucket + sliding window.

Bot detection: behavioral analysis, CAPTCHA challenge (dla web endpoints), fingerprinting.

IP reputation: integracja z threat intelligence feeds. Known-bad IPs → block.

Geo-blocking: opcjonalne per-operator (np. operator STATE może ograniczyć dostęp do IP z EU).

Komunikacja dozwolona:

Zone 0 → Zone 1 (ingress): IPsec / HTTPS

Zone 1 → Zone 2 (egress): internal HTTPS / gRPC (mTLS)

Zone 1 → Zone 4 (egress): auth verification (OIDC endpoints)

Zone 1 ← Internet (ingress): API endpoints, webhooks

63.3 Zone 2 — G1/G2 Split Gateway

Status: [N] Normatywny Odbiorca: Security Architect, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.6, 65.4, 65.6

Zone 2 implementuje G1/G2 Split Gateway — kluczowy pattern bezpieczeństwa SYLION rozdzielający metadata/control (G1) od payload/media (G2).

G1 (Gateway 1 — Control Plane):

Odpowiada za: session brokering, policy enforcement, authentication relay, session lifecycle management. - Widzi: metadane sesji (kto, kiedy, jaki typ, jaka polityka).

- Nie widzi: treści komunikacji, zawartości plików, pixeli renderowanych sesji. - Deployment: dedicated VMs/pods, hardened, minimalna powierzchnia ataku.

G2 (Gateway 2 — Data Plane):

Odpowiada za: przekazywanie pixel stream (remote desktop), media relay (audio/video), file transfer relay. - Widzi: zaszyfrowane strumienie danych (E2EE lub transport encryption). - Nie widzi: metadanych sesji zarządzanych przez G1, polityk, tożsamości użytkownika. - Blind Broker: dla audio/video — SFrame/WebRTC Insertable Streams zapewniają, że G2 nie może odszyfrować treści.

Uwaga — Blind Broker dla remote desktop:

Blind broker jest zwalidowany dla kanałów audio/video (SFrame). Dla kanału remote desktop (Guacamole-based) blind broker nie jest zwalidowany — CVE-2024-35164 (RCE w Apache Guacamole) oznacza, że G2 ma potencjalny dostęp do pixel stream. Status: [E] (Eksperymentalny). Mitygacja: patching Guacamole, sandboxing G2 w microVM, monitoring anomalii.

Separacja G1/G2:

G1 i G2 są osobnymi procesami/VM na osobnych nodach. Komunikacja G1 ↔ G2: wyłącznie session control signals (start, stop, pause) przez mTLS. G2 nie ma dostępu do bazy danych G1, Vault, ani policy engine.

63.4 Zone 3 — Workloads

Status: [N] Normatywny Odbiorca: Security Architect, DevSecOps, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.5, 64.7, 68.4

Zone 3 to strefa operacyjna, w której działają workloady operatorów: microVM z desktopami, aplikacje, kontenery procesów biznesowych.

Izolacja per-operator:

Dedykowany network namespace (Kubernetes namespace lub VLAN) per-operator.

Firecracker microVM per-sesja lub per-workload (zależnie od konfiguracji).

SEV-SNP/TDX: pamięć workloadu zaszyfrowana kluczem sprzętowym — nawet hypervisor nie ma dostępu do plaintext (z zastrzeżeniem residual risk — patrz 64.7).

Osobna baza danych per-operator (logical isolation via RLS, physical isolation opcjonalnie dla STATE).

Dostęp do danych:

Workload operatora ma dostęp wyłącznie do danych swojego operatora (RLS + network policy).

Cross-operator access: niemożliwy by design (separate network, separate DB rows, separate encryption keys).

Admin access do Zone 3: wyłącznie w trybie incydentu (break-glass), logowany, ograniczony czasowo.

Komunikacja dozwolona:

Zone 2 → Zone 3: pixel stream, media stream (via G2). Control signals (via G1).

Zone 3 → Zone 4: database access, Vault, event broker, search index.

Zone 3 → External: deny-default. Whitelist per-operator (jeśli operator wymaga dostępu do internetu).

Zone 3 → Zone 3 (intra-zone): dozwolona w obrębie tego samego operatora. Zablockowana cross-operator.

63.5 Zone 4 — Shared Services

Status: [N] Normatywny Odbiorca: Architekt, DBA, DevSecOps Wpływ na baseline: Wysoki Powiązane rozdziały: 58.1, 58.6, 58.7

Zone 4 zawiera usługi współdzielone: bazy danych, Vault, event broker, search index, adaptery integracyjne.

Zasada: Zone 4 jest „utility layer” — dostarcza usługi dla Zone 3 i Zone 5. Nie inicjalizuje komunikacji do stref klienckich (Zone 0, Zone 1).

Izolacja w Zone 4:

Logical tenant isolation: RLS w bazach danych, namespace isolation w Vault, topic ACL w event broker.

Network: mikrosegmentacja — każda usługa w osobnym namespace. PostgreSQL dostępny wyłącznie z Zone 3/5 (per-service). Vault dostępny z Zone 3/4/5 (per-path policy).

Secrets: Vault secrets engine per-tenant (dynamic credentials).

Komunikacja dozwolona:

Zone 3 → Zone 4: database queries, Vault API, event broker publish/subscribe.

Zone 5 → Zone 4: management operations (DB maintenance, Vault admin, broker config).

Zone 4 → External: adaptery integracyjne (SIEM, ITSM, IdP) — per-adapter egress whitelist.

Zone 4 → Zone 3: event delivery (push notifications, webhook callbacks) — via event broker.

63.6 Zone 5 — Management

Status: [N] Normatywny Odbiorca: CISO, Security Architect, Platform Admin Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.3, 64.11, 66.1

Zone 5 jest najbardziej chronioną strefą — management plane. Zawiera: orchestrator platformy, CI/CD, konfigurację globalną, root Vault, monitoring centralny.

Dostęp:

Wyłącznie z dedykowanej sieci administracyjnej (bastion host / VPN z FIDO2).

Brak dostępu z Zone 0–3 (zero trust od dołu do góry).

Zone 4 → Zone 5: ograniczony do telemetrii (metrics, logs — push model).

Każdy dostęp logowany, Four-Eyes dla operacji destrukcyjnych.

Crown jewels w Zone 5:

Vault root (HSM-backed keys).

CI/CD pipeline (supply chain).

Orchestrator (może provisionować/destroy workloady).

Global config (polityki, routing, certyfikaty root).

Backup encryption keys.

Kompromitacja Zone 5 = kompromitacja całej platformy. Defense-in-depth Zone 5 jest najgłębsze (patrz 62.5).

63.7 Autonomiczny perymetr [A]

Status: [A] Autonomiczny Odbiorca: Architekt, CISO (STATE tier) Wpływ na baseline: Niski (opcjonalny dla STATE) Powiązane rozdziały: 63.1–63.6, 64.8

Autonomous Perimeter to opcjonalna konfiguracja dla operatorów STATE wymagających pełnej suwerenności: cała infrastruktura SYLION (Zone 1–5) deployowana w dedykowanym, fizycznie izolowanym środowisku operatora.

Charakterystyka:

Fizyczna izolacja: dedykowane serwery, rack, datacenter.

Brak łączności z infrastrukturą SYLION SaaS.

Operator zarządza kluczami (BYO-KMS, BYO-HSM).

Aktualizacje: offline delivery (podpisane artefakty na nośniku).

Monitoring: wyłącznie wewnętrzny (brak telemetrii do SYLION).

Trade-off:

Autonomous Perimeter zapewnia najwyższy poziom izolacji, ale operator przejmuje odpowiedzialność za operacje (patching, monitoring, backup). SYLION dostarcza support w modelu consulting, nie managed service.

63.8 Granice zaufania — jawna lista decyzji zaufania

Status: [N] Normatywny Odbiorca: Security Architect, Auditor Wpływ na baseline: Krytyczny Powiązane rozdziały: 63.1–63.6, 64.1

SYLION jawnie dokumentuje każdą decyzję zaufania (trust decision) w architekturze:

Trust Decision	Zaufanie	Uzasadnienie	Residual Risk
----------------	----------	--------------	---------------

Endpoint (Zone 0)	UNTRUSTED	Fizyczny dostęp atakującego realistyczny	Credential theft via malware
API Gateway (Zone 1)	CONDITIONALLY TRUSTED	Managed by SYLION, internet-facing	DDoS, zero-day in gateway
G1 (Zone 2)	TRUSTED for metadata	Control plane, no data access	Session metadata leak
G2 (Zone 2)	PARTIALLY TRUSTED	Data plane, encrypted streams	Guacamole CVE [E]
Workload (Zone 3)	TRUSTED within operator scope	Isolated per-operator	MicroVM escape (residual)
Shared Services (Zone 4)	TRUSTED	Internal, managed by SYLION	Supply chain, insider
Management (Zone 5)	HIGHLY TRUSTED	Most protected, limited access	Insider with Four-Eyes bypass
Cloud Provider	UNTRUSTED for data	Infrastructure only, data encrypted	Legal jurisdiction, SEV-SNP limits
External IdP	CONDITIONALLY TRUSTED	Authentication delegation	IdP compromise
Event Broker	TRUSTED for delivery	Internal, mTLS, ACL	Data-in-transit if TLS fails

Zero Trust principle: Każda granica jest punktem weryfikacji. Przejście między strefami wymaga re-authentication/re-authorization.

63.9 Dozwolone vs zabronione przepływy — pełna matryca

Status: [N] Normatywny Odbiorca: Network Engineer, Security Architect, Auditor Wpływ na baseline: Krytyczny Powiązane rozdziały: 63.1–63.6, 62.4

Matryca przepływów (source → destination):

Source ↓ / Dest →	Zone 0	Zone 1	Zone 2	Zone 3	Zone 4	Zone 5	Internet
Zone 0	—	✓ IPsec	✗	✗	✗	✗	✗ (via SYLION only)
Zone 1	✗	—	✓ mTLS	✗	✓ Auth only	✗	✓ Webhooks
Zone 2	✗	✓ Response	—	✓ Stream/Control	✓ Policy query	✗	✗
Zone 3	✗	✗	✓ Stream return	intra-op ✓	✓ DB/Vault/Broker	✗	⚠ Whitelist only
Zone 4	✗	✗	✗	✓ Events/callbacks	intra-zone ✓	✓ Telemetry	✓ Integrations
Zone 5	✗	✗	✓ Config push	✓ Orchestration	✓ Management	—	✓ Updates

Legendia: ✓ = dozwolony (z mTLS/IPsec), ✗ = zabroniony, ⚠ = warunkowo (za zgodą operatora).

Enforcement:

Matryca egzekwowana na trzech warstwach: 1. Kubernetes NetworkPolicy (L3/L4). 2. Service mesh authorization policy (L7). 3. Firewall rules (infrastructure level).

Każda zmiana matrycy wymaga: propozycja → security review → dual authorization → deployment → verification test.

63.10 Monitoring międzystrefowy

Status: [N] Normatywny Odbiorca: SOC, SRE, Network Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 63.9, 67.10, 68.7

Monitoring przepływów międzystrefowych jest krytyczny dla wykrywania lateral movement i nieautoryzowanej komunikacji.

Mechanizmy:

Network flow logs: każdy pakiet przechodzący granicę strefy jest logowany (source IP, dest IP, port, protocol, bytes, timestamp). Flow logs → WORM store + search index.

Service mesh telemetry: Envoy sidecar raportuje każdy request (source service, dest service, method, path, status, latency). Telemetria → VictoriaMetrics.

Anomaly detection: ML-based baseline zachowań komunikacyjnych. Alerty na: nieoczekiwana para source-dest, nietypowy wolumen, nietypowy port/protokół, komunikacja w nietypowej godzinie.

NetworkPolicy audit: periodic scan weryfikujący, że zaimplementowane NetworkPolicy odpowiadają matrycy (63.9). Drift → alert.

Dashboard:

Real-time network map: wizualizacja aktywnych przepływów między strefami. Color-coded: zielony = dozwolony, czerwony = zablokowany (policy deny), żółty = anomalia.

63.11 Walidacja segmentacji — testowanie

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect, QA Wpływ na baseline: Wysoki Powiązane rozdziały: 63.9, 70.6, 70.7

Segmentacja sieci musi być regularnie testowana aby potwierdzić, że matryca przepływów jest poprawnie egzekwowana.

Testy automatyczne (CI/CD):

Network canary tests: po każdym deployment, automated tests próbują nawiązać połączenia na zabronionych ścieżkach (np. Zone 3 → Zone 5). Oczekiwany wynik: connection refused/timeout. Sukces = segmentacja działa.

Policy validation: kubectl get networkpolicy → porównanie z desired state (GitOps).

Testy manualne (quarterly):

Red team: próba lateral movement z Zone 3 do Zone 5.

Network scanning: nmap z Zone 3 — żadne porty Zone 5 nie powinny odpowiadać.

Egress testing: próba exfiltration z Zone 3 (curl external) — powinno być zablokowane (chyba że whitelistowane).

Raportowanie:
Wyniki testów segmentacji → compliance report. Nieprzejdzie testu = P1 defect → natychmiastowa naprawa. Testy archiwizowane w WORM store (evidence).

Rozdział 64. Model zagrożeń i przeciwnicy

64.1 Kategorie przeciwników — 7 klas z możliwościami i motywacjami

Status: [N] Normatywny Odbiorca: CISO, Security Architect, SOC, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.2–64.13, 62.1, 71.1
SYLION definiuje siedem klas przeciwników uporządkowanych według rosnących możliwości (capabilities). Model zagrożeń jest projektowany tak, aby adresować każdą klasę odpowiednimi kontrolkami, z jawną identyfikacją ryzyka rezydualnego.

#	Klasa	Motywacja	Możliwości	Przykład
1	Oportunistyczny atakujący	Zysk finansowy, chaos	Publiczne exploit kity, skrypty, phishing	Script kiddie, ransomware bot
2	Zorganizowana grupa przestępcza	Zysk finansowy (duży)	Custom malware, social engineering, insider recruitment	APT z motywacją finansową
3	Aktor szpiegostwa korporacyjnego	Przewaga konkurencyjna	Targeted attacks, insiderzy, legal pressure	Konkurencyjne firmy, firmy wywiadowcze
4	Państwowe służby wywiadowcze (SIGINT)	Inwigilacja, geopolityka	Pełne zdolności cyber (0-days, supply chain, hardware implants), zdolności telekom (SS7, IMSI catchers), presja prawna, zdolności HUMINT	NSA, GRU, MSS, BND
5	Złośliwy insider	Osobiste/finansowe	Uprzywilejowany dostęp, znajomość systemów, omijanie kontroli	Administrator z dostępem, rekrutowany pracownik
6	Wrogі hypervisor / cloud provider	Compliance, inwigilacja, komercyjny	Pełny dostęp do infrastruktury fizycznej, pamięci VM, storage	Skompromitowany cloud provider, hosting provider pod presją
7	Aktor prawno-procesowy	Legalny dostęp do danych	Nakazy sądowe, zajęcie serwerów, wymuszenie kluczy	Prokuratura, sąd, regulator

Priorytetyzacja:
SYLION musi zapewniać silną ochronę przed klasami 1–3 (odporność z high confidence). Dla klas 4–7 — defense-in-depth z jawnie opisanym ryzykiem rezydualnym (żadna platforma nie gwarantuje 100% ochrony przed nation-state z fizycznym dostępem do infrastruktury).

64.2 Atakujący sieciowy — TTP, mitygacje, ryzyko rezydualne

Status: [N] Normatywny Odbiorca: Security Architect, SOC, Network Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 65.1, 67.2, 67.3
TTP (Tactics, Techniques, Procedures):
Reconnaissance: skanowanie portów, DNS enumeration, OSINT na infrastrukturze SYLION.
Initial Access: exploit na internet-facing services (API Gateway, VPN endpoint), credential stuffing, phishing.
Man-in-the-Middle: próba przechwycenia komunikacji (ARP spoofing w LAN, DNS hijacking, BGP hijacking).
Denial of Service: volumetric DDoS (L3/L4), application-layer DDoS (L7), slowloris.
Mitygacje SYLION:

TTP	Mitygacja	Warstwa
Recon	Minimal surface (only API Gateway exposed), no version banners, rate limiting on probes	Zone 1
Credential stuffing	FIDO2 (eliminuje phishing), rate limiting na auth endpoints, IP reputation	Zone 1
MITM	IPsec IKEv2 (cert-based auth), mTLS everywhere, certificate pinning	Zone 0→1, all internal
DDoS	CDN-based DDoS protection, rate limiting, auto-scaling Zone 1, geo-blocking	Zone 1

Ryzyko rezydualne:
Zero-day w API Gateway (Envoy, Kong): mitygowane przez WAF + rapid rebuild.
BGP hijacking: mitygowane przez RPKI (jeśli provider wspiera), cert pinning.
DDoS at scale (nation-state): możliwa degradacja dostępności pomimo CDN.

64.3 Złośliwy operator — TTP, mitygacje, ryzyko rezydualne

Status: [N] Normatywny Odbiorca: CISO, Security Architect, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.3, 64.5, 64.10
Operator z uprawnieniami administracyjnymi stanowi jednego z najpoważniejszych przeciwników — posiada legalny dostęp i znajomość systemu.

TTP:

Privilege abuse: wykorzystanie uprawnień admina do dostępu do danych innych operatorów lub management plane.
Data exfiltration: eksport danych własnego operatora (legalne) lub próba dostępu do danych innych operatorów (nielegalne).
Sabotaż: destrukcja konfiguracji, polityk, certyfikatów.
Log tampering: próba usunięcia/modyfikacji logów audytowych.
Social engineering: przekonanie support SYLION do nadania dodatkowych uprawnień.

Mitygacje:

Tenant isolation: operator widzi wyłącznie dane swojego tenanta. RLS, network isolation, encryption per-operator.

Four-Eyes: operacje destrukcyjne wymagają dual authorization. Operator admin nie może samodzielnie usunąć danych.

WORM audit logs: logi nie mogą być modyfikowane — nawet przez platformę. Hash chains weryfikowalne.

Privilege boundaries: operator admin nie ma dostępu do management plane (Zone 5). Eskalacja niemożliwa bez dodatkowej autoryzacji.

Behavioral monitoring: anomaly detection na aktywności operatora (nietypowe godziny, nietypowy wolumen operacji, dostęp do rzadko używanych endpointów).

SOC oversight: SOC monitoruje aktywność operatorów (meta-level, bez dostępu do treści).

Ryzyko rezydualne:

Operator z legalnymi uprawnieniami może exfiltrować dane swojego operatora (dozwolone — to jego dane).

Kompromitacja dwóch adminów tego samego operatora (Four-Eyes bypass) — mitygowane przez dodatkowe kontrolki: notification, anomaly detection, time-based restrictions.

64.4 Kompromitacja terminala — powierzchnia ataku, mitygacje, ryzyko rezydualne

Status: [N] Normatywny Odbiorca: Security Architect, Endpoint Admin Wpływ na baseline: Wysoki Powiązane rozdziały: 63.1, 71.1, 71.2

Powierzchnia ataku:

Fizyczny dostęp: kradzież laptopa, konfiskata urządzenia.

Malware: trojan, keylogger, screen capture.

Evil maid: modyfikacja firmware/bootloader podczas nieobecności użytkownika.

Mitygacje:

Zero local data: thin client nie przechowuje danych. Po zamknięciu sesji — brak artefaktów.

Full-disk encryption: LUKS/BitLocker z pre-boot authentication.

Secure Boot + TPM: weryfikacja integralności bootchain. Evil maid → attestation failure → sesja odrzucona.

FIDO2: phishing-resistant authentication. Keylogger nie przechwytuje FIDO2 challenge.

Session timeout: auto-disconnect po N minut nieaktywności (konfigurowane: 5–30 min).

Remote wipe: MDM-based remote wipe w przypadku kradzieży.

Duress PIN (STATE): sygnalizacja przymusu bez wiedzy atakującego.

Ryzyko rezydualne:

Aktywna sesja z malware: malware może przechwytywać pixel stream w trakcie aktywnej sesji (screen capture, OCR). Mitygacja: micro-watermarking [O] (identyfikacja źródła wycieku).

Shoulder surfing: brak mitygacji technicznej (fizyczne bezpieczeństwo po stronie użytkownika).

Kompromitacja FIDO2 tokenu: ekstremalnie trudna (hardware security element), ale nie niemożliwa (side-channel attacks na specyficznych implementacjach).

64.5 Kompromitacja routera — powierzchnia ataku, mitygacje

Status: [N] Normatywny Odbiorca: Security Architect, Network Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 63.1, 65.1, 71.3

Powierzchnia ataku:

Router pomiędzy Zone 0 a Zone 1 (ISP router, corporate router) jest poza kontrolą SYLION.

Traffic interception: atakujący z kontrolą routera widzi cały ruch.

Traffic manipulation: wstrzykiwanie/modyfikacja pakietów.

Traffic analysis: analiza metadanych (timing, volume, destinations).

Mitygacje:

IPsec IKEv2: end-to-end encryption Zone 0 → Zone 1. Router widzi wyłącznie zaszyfrowane ESP pakiety. Brak dostępu do plaintext.

Certificate-based auth (IKEv2): router nie może wykonać MITM — certyfikat gateway Zone 1 weryfikowany przez klienta.

PFS (Perfect Forward Secrecy): nawet jeśli router przechwyci ruch i później zdobędzie klucz prywatny, nie odszyfruje wcześniej przechwyconego ruchu.

Traffic padding [O]: opcjonalne generowanie dummy traffic aby utrudnić traffic analysis. Zwiększa zużycie bandwidth — dostępne dla tier STATE.

Ryzyko rezydualne:

Traffic analysis: atakujący widzi timing, volume, destination IP. Może wnioskować o aktywności użytkownika (np. „użytkownik jest online o 14:00”). Mitygacja: traffic padding [O], VPN jako dodatkowa warstwa.

DoS: router może blokować ruch do SYLION. Brak mitygacji technicznej (zależność od connectivity).

64.6 Kompromitacja session brokera — analiza SPOF, Guacamole CVE-2024-35164

Status: [N] Normatywny Odbiorca: Security Architect, SOC, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 63.3, 65.4, 71.6

Analiza SPOF:

Session broker (Zone 2) jest potencjalnym Single Point of Failure i Single Point of Compromise: przechodzi przez niego cały ruch sesyjny.

Kompromitacja session brokera → dostęp do: metadanych sesji (kto, kiedy, jaki typ), pixel stream (jeśli E2EE nie jest aktywne), możliwość terminacji/przechwycenia sesji.

Guacamole CVE-2024-35164:

Apache Guacamole (wykorzystywany jako komponent session brokera dla remote desktop) podatny na CVE-2024-35164 — Remote Code Execution. Implikacje:

Atakujący z RCE na Guacamole uzyskuje wykonanie kodu w Zone 2.

Może przechwycić pixel stream aktywnych sesji desktop.

Może manipulować sesjami (injection klawiszy, mouse events).

Mitygacje:

Patching: natychmiast po publikacji CVE (emergency patch workflow).

Sandboxing: Guacamole uruchamiany w dedykowanym microVM (Firecracker) z SEV-SNP. Blast radius: jeden node brokera, nie cała platforma.

Horizontal scaling: wiele instancji brokera. Kompromitacja jednej = kompromitacja sesji na tym nodzie (nie wszystkich).

Anomaly detection: monitoring zachowania procesu Guacamole (unexpected syscalls, network connections, file access) przez eBPF/Tetragon.

Credential limitation: broker ma dostęp wyłącznie do session metadata DB. Brak dostępu do Vault, policy engine (beyond query), management plane.

Alternative exploration [E]: badanie alternatyw dla Guacamole (własna implementacja pixel streaming) — status eksperymentalny.

Ryzyko rezydualne:

Guacamole CVE jest realnym ryzykiem. SYLION nie gwarantuje blind broker dla kanału remote desktop. Klienci STATE powinni być świadomi tego ograniczenia.

Defense-in-depth (microVM, SEV-SNP, monitoring) minimalizuje blast radius, ale nie eliminuje ryzyka.

64.7 Hostile hypervisor — cloud provider risk, SEV-SNP + TDX, analiza CVE

Status: [N] Normatywny Odbiorca: CISO, Security Architect, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.8, 64.8, 71.8

Scenariusz:

Cloud provider (lub atakujący z dostępem do hypervisora) próbuje odczytać pamięć VM SYLION, zmodyfikować workloady lub przechwycić dane.

AMD SEV-SNP:

SEV-SNP (Secure Encrypted Virtualization — Secure Nested Paging) szyfruje pamięć VM kluczem sprzętowym niedostępnym dla hypervisora. SYLION stosuje SEV-SNP jako obronę w głąb (defense-in-depth), ale jawnie dokumentuje ograniczenia:

CVE-2024-56161: podatność w AMD SEV-SNP firmware — umożliwia wstrzyknięcie złośliwego mikro kodu i ominięcie attestation.

Atak „Battering RAM” (KU Leuven): atak side-channel na SEV-SNP — umożliwia odczyt pamięci gościa z precyzją 4KB strony.

Statystyki CVE: SEV-SNP ma 49 CVE w historii (wobec 9 CVE dla Intel TDX). Trend wskazuje na ciągłe odkrywanie nowych podatności.

Intel TDX:

TDX (Trust Domain Extensions) jest alternatywą z mniejszą liczbą CVE (9 na dzień pisania), ale: - Mniejsza dostępność w cloud (ograniczone do wybranych instancji Azure/GCP). - Mniej przetestowany w produkcji (nowszy). - Brak gwarancji braku przyszłych CVE.

Stanowisko SYLION:

SEV-SNP/TDX to wartościowa warstwa obrony (defense-in-depth), ale NIE absolutna gwarancja ochrony przed hostile hypervisor. SYLION: 1. Wymaga SEV-SNP lub TDX tam, gdzie dostępne. 2. Implementuje attestation (weryfikacja integralności VM przed uruchomieniem). 3. NIE polega wyłącznie na TEE — stosuje dodatkowe warstwy: encryption at-rest (osobne klucze), network isolation, monitoring, short-lived credentials. 4. Dla najwyższego bezpieczeństwa (STATE): autonomous perimeter [A] — eliminacja cloud provider z trust boundary.

64.8 Cloud provider risk — wymiar prawny, techniczny, operacyjny

Status: [N] Normatywny Odbiorca: CISO, Legal, Compliance, Architekt Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.7, 59.2, 64.11

Wymiar prawny:

CLOUD Act (US): US cloud providers (AWS, Azure, GCP) mogą być zobowiązani do udostępnienia danych przechowywanych poza USA na żądanie US authorities. Mitygacja: encryption at-rest z BYO-KMS (provider nie ma klucza), sovereign cloud regions (EU-operated).

Lokalne regulacje: GDPR (EU), CCPA (California), BSI requirements (Germany). Compliance wymaga: data residency (dane nie opuszczają jurysdykcji), audit trails, prawo do usunięcia.

Nakaz sądowy wobec cloud provider: provider może być zobowiązany do udostępnienia infrastruktury (VM snapshots, network captures). Mitygacja: SEV-SNP (memory encryption), encryption at-rest (key in Vault, nie u providera).

Wymiar techniczny:

Provider ma fizyczny dostęp do hardware (może wykonywać cold boot attacks, memory dumps, firmware modifications).

Provider kontroluje sieć (może wykonywać traffic analysis, man-in-the-middle na nie-szyfrowanych warstwach).

Provider kontroluje storage (może czytać dane at-rest jeśli nie zaszyfrowane kluczem klienta).

Wymiar operacyjny:

Provider outage: single-region outage może wyłączyć SYLION. Mitygacja: multi-region deployment (STATE), health checks, DR plan.

Provider pricing changes: vendor lock-in risk. Mitygacja: cloud-agnostic architecture (Kubernetes, Terraform).

Provider account suspension: błąd, fraud detection, TOS violation. Mitygacja: documented escalation path, backup deployment.

Rekomendacja per-tier:

Tier	Rekomendacja
STANDARD	Cloud deployment z encryption at-rest (provider-managed keys akceptowalne)
PRO	Cloud deployment z BYO-KMS, sovereign region
STATE	Autonomous perimeter [A] lub sovereign cloud z BYO-HSM

64.9 SIGINT i telekomunikacja — SS7, IMSI catchers, tower dumps, mitygacje

Status: [N] Normatywny Odbiorca: CISO, Security Architect, SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 63.1, 65.1, 71.4

SS7 (Signaling System 7):

Protokół telekomunikacyjny z lat 80. bez wbudowanych zabezpieczeń. Atakujący z dostępem do SS7 (wymaga operatora telekomunikacyjnego lub exploitu) może: - Przechwycić SMS (kody 2FA — dlatego SYLION wymaga FIDO2, nie SMS). - Lokalizować urządzenie (cell-level tracking). - Przekierować połączenia.

Mitygacja SYLION: brak zależności od SMS/voice dla uwierzytelniania (FIDO2 only). Komunikacja via IPsec, nie SS7.

IMSI Catchers (Stingrays):

Fałszywe stacje bazowe, które podszywają się pod operatora komórkowego. Mogą: - Przechwycić IMSI urządzenia (identyfikacja). - Wymusić downgrade szyfrowania (2G/3G bez encryption). - Przechwycić ruch danych (jeśli 2G).

Mitygacja SYLION: IPsec tunnel (niezależny od szyfrowania warstwy telekomunikacyjnej). IMSI catcher widzi zaszyfrowany tunel IPsec. Opcjonalnie: IMSI rotation (legalna — Cape MVNO commercial offering). Uwaga: IMEI modification jest nielegalna w EU/UK/India/Australia — SYLION NIE wspiera ani nie rekomenduje modyfikacji IMEI.

Tower dumps:

Operator telekomunikacyjny (na żądanie służb) przekazuje listę wszystkich urządzeń podłączonych do danej stacji bazowej w określonym czasie.

Mitygacja: IMSI rotation (legalna). Brak korelacji IMSI z tożsamością SYLION (SYLION nie przechowuje IMSI). Lokalizacja użytkownika nie ujawnia treści komunikacji (IPsec + E2EE).

Ryzyko rezydualne:

Metadane telekomunikacyjne (cell tower, timing) dostępne dla operatora telekom i służb. SYLION nie kontroluje warstwy telekomunikacyjnej.

Korelacja timing: jeśli atakujący zna czas sesji SYLION i ma tower dumps, może korelować tożsamość. Mitygacja: traffic padding [O], VPN jako dodatkowa warstwa.

64.10 Insider i wyciek optyczny — micro-watermarking [O], logowanie sesji, kontrolki polityk

Status: [N] Normatywny (logowanie, polityki) / [O] Opcjonalny (watermarking) Odbiorca: CISO, Security Architect, SOC, HR Wpływ na baseline: Wysoki Powiązane rozdziały: 64.3, 71.12, 71.13

Scenariusz:

Insider (użytkownik z autoryzowanym dostępem do sesji) fotografuje ekran, kopiuje dane na papier lub nagrywa sesję zewnętrznym urządzeniem. Atak „optical gap” — exfiltracja danych z pominięciem kontroli technicznych.

Micro-watermarking [O]:

SYLION oferuje opcjonalny (tier STATE) system micro-watermarkingu — steganograficzne znaki wodne osadzone w pixel streamie (metoda DCT — Discrete Cosine Transform):

Imperceptible: niewidoczne gołym okiem, nie wpływają na UX.

Per-session: każda sesja ma unikalny watermark (session ID + user ID + timestamp).

Forensic: jeśli wyciek zostanie wykryty (zdjęcie/nagranie z ekranu), watermark umożliwia identyfikację źródła.

Odporność: watermark przeżywa kompresję JPEG, skalowanie, częściowe przycięcie.

Status: [O] (Opcjonalny) — wymaga dodatkowej konfiguracji i zasobów (CPU overhead ~5%).

Logowanie sesji:

Session recording (opcjonalne, per-policy): nagrywanie pixel stream sesji do encrypted storage.

Zastosowanie: compliance (finanse, administracja publiczna), forensics po incydencie.

Bezpieczeństwo: nagrania szyfrowane kluczem operatora (BYO-KMS). SYLION nie ma dostępu do nagrań.

Retencja: konfigurowalna per-operator (30 dni — 24 miesiące).

Dostęp do nagrań: dual authorization (Four-Eyes).

Kontrolki polityk:

Clipboard control: blokada kopiuj/wklej między sesją a lokalnym systemem (domyślnie zablokowane, odblokowane per-policy).

- Print control: blokada drukowania (domyślnie zablokowane).
- Download control: blokada pobierania plików z sesji na lokalny system (domyślnie zablokowane, CDR dla dozwolonych).
- USB redirection: zablokowane domyślnie.
- Screen capture detection: wykrywanie prób rzutów ekranu (na poziomie thin client — ograniczona skuteczność).

64.11 Działania prawno-procesowe — strategia jurysdykcyjna, minimalizacja danych, szyfrowanie przy zajęciu

Status: [N] Normatywny Odbiorca: CISO, Legal, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.8, 58.4, 62.9

Scenariusz:

Organy ścigania lub regulator żądają dostępu do danych SYLION: nakaz sądowy, zajęcie serwerów, żądanie przekazania kluczy szyfrujących.

Strategia jurysdykcyjna:

Data residency: dane operatora przechowywane w jurysdykcji operatora (EU, DE, PL — zależnie od deployment). Brak automatycznego transferu cross-border.

Legal entity separation: SYLION może operować w wielu jurysdykcjach jako osobne podmioty prawne. Nakaz w jednej jurysdykcji nie dotyczy danych w innej.

Operator sovereignty (STATE): autonomous perimeter — dane pod pełną kontrolą operatora. SYLION nie posiada kluczy i nie może udostępnić plaintext danych.

Minimalizacja danych (pre-emptive defense):

SYLION nie przechowuje treści komunikacji (E2EE).

Metadane minimalizowane (patrz 62.9).

Krótkie retencje (dane usuwane automatycznie).

Brak centralnego repozytorium wszystkich danych operatorów — database-per-service, per-operator isolation.

Szyfrowanie przy zajęciu (encrypted-at-seizure):

Jeśli serwery fizycznie zajęte: 1. At-rest encryption: dane na dyskach zaszyfrowane (LUKS). Klucze w Vault (HSM-backed). Zajęcie dysku bez klucza = dostęp do ciphertext. 2. Vault seal: jeśli Vault jest restarted (power off) — automatycznie sealed. Unseal wymaga KMS lub HSM tokenu. Fizyczne zajęcie serwera bez KMS/HSM → Vault sealed → dane niedostępne. 3. Memory encryption (SEV-SNP/TDX): pamięć VM zaszyfrowana sprzętowo. Cold boot attack nie daje plaintext. 4. Short-lived credentials: tokeny, certyfikaty serwisowe — wygasają w ciągu minut/godzin. Zajęty serwer z wygasłymi credentials jest bezużyteczny. 5. Auto-lockdown: wykrycie anomalii (nagły shutdown wielu nodów) → automated lockdown: Vault sealed, sessions terminated, alerts to SOC.

64.12 Model ryzyka rezydualnego — jakie ryzyka pozostają po wszystkich kontrolkach

Status: [N] Normatywny Odbiorca: CISO, Board, Compliance, Auditor Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.1–64.11, 71.16

Jawna dokumentacja ryzyk rezydualnych jest fundamentem uczciwego security posture.

Ryzyka rezydualne:

#	Ryzyko	Kontrolki	Ryzyko rezydualne	Poziom
R1	Zero-day w core component	WAF, monitoring, rebuild-first	Exploitation window (hours)	Średni
R2	SEV-SNP/TDX bypass	TEE + network isolation + encryption	CVE history suggests future bypasses	Średni
R3	Nation-state targeted attack	All layers	Sufficient resources may overcome any defense	Wysoki
R4	Insider with physical access to HSM	HSM tamper-detection, dual control	Physical attack on HSM	Niski
R5	Supply chain (0-day in dependency)	SBOM, SCA, pinning, signing	Sophisticated supply chain (xz-utils style)	Średni
R6	Guacamole remote desktop channel	Patching, sandboxing, monitoring	Blind broker not validated [E]	Wysoki
R7	Legal compulsion in unfavorable jurisdiction	BYO-KMS, sovereign deployment, legal structure	Court may compel key disclosure	Wysoki
R8	Optical leak (screen photography)	Watermarking [O], policies	Physical observation unmitigable	Wysoki
R9	Metadata correlation (traffic analysis)	Traffic padding [O], IPsec	Sophisticated traffic analysis	Średni
R10	Two-insider collusion (Four-Eyes bypass)	Notification, anomaly detection, time restrictions	Coordinated insider attack	Niski

Akceptacja ryzyka:

Każde ryzyko rezydualne musi być formalnie zaakceptowane przez CISO i udokumentowane. Przegląd co 6 miesięcy. Nowe CVE lub zmiany w krajobrazie zagrożeń mogą zmienić ocenę ryzyka.

64.13 Crown jewels — management plane, system automatyzacji, menedżer tajemnic, środowiska operatorów, klucze komunikacyjne, logi, broker dostępu

Status: [N] Normatywny Odbiorca: CISO, Security Architect, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 63.6, 62.3, 66.1

Crown jewels to aktywa o najwyższej wartości, których kompromitacja ma katastrofalny wpływ na platformę.

Identyfikacja crown jewels:

Crown Jewel	Lokalizacja	Wpływ kompromitacji	Ochrona
Management Plane	Zone 5	Pełna kontrola nad platformą	Most restricted zone, FIDO2+Four-Eyes, audit
Vault Root Keys	HSM (Zone 5)	Dostęp do wszystkich tajemnic	FIPS 140-3 L3 HSM, dual control, break-glass

CI/CD Pipeline	Zone 5	Supply chain compromise	Ephemeral runners, signed artifacts, SLSA L3
Automation System (Orchestrator)	Zone 5	Provision/destroy workloads	RBAC, Four-Eyes for destructive ops
Operator Environments	Zone 3	Data breach per-operator	microVM, SEV-SNP, RLS, per-operator keys
Communication Keys (E2EE)	Zone 3 (in-memory)	Decrypt communications	Per-session keys, PFS, short-lived
Audit Logs	Zone 4 (WORM)	Evidence tampering	WORM, hash chains, external timestamping
Session Broker	Zone 2	Session hijacking	Horizontal scaling, sandboxing, monitoring
DNS Configuration	Zone 1/External	Traffic redirection	DNSSEC, monitoring, split-horizon DNS

Ochrona crown jewels:

Dla każdego crown jewel: 1. Access: minimal (least privilege), logged, Four-Eyes for modification. 2. Monitoring: real-time alerting on any access/modification. 3. Backup: encrypted, tested, separate from operational infrastructure. 4. Recovery: documented procedure, tested quarterly. 5. Destruction: secure destruction procedure (crypto-shredding for data, HSM zeroization for keys).

Rozdział 65. Bezpieczne wzorce komunikacji

Bezpieczne wzorce komunikacji

65.1 Wzorce IPsec — SA establishment, PFS, rekeying

Status: [N] Normatywny Odbiorca: Network Engineer, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 63.1, 64.5, 65.9

IPsec z IKEv2 stanowi fundamentalny mechanizm szyfrowania komunikacji między Zone 0 (endpoint) a Zone 1 (access layer).

SA (Security Association) Establishment:

Nawiązanie tunelu IPsec w SYLION wymaga dwufazowego procesu IKEv2: 1. IKE_SA_INIT: wymiana Diffie-Hellman (ECDH P-384 lub X25519), negocjacja algorytmów. SYLION wymaga: AES-256-GCM (encryption), SHA-384 (integrity), ECDH P-384 lub X25519 (DH group). 2. IKE_AUTH: uwierzytelnianie za pomocą certyfikatów X.509 (device cert + gateway cert). EAP-TLS jako fallback (dla urządzeń bez hardware cert store). Password-based auth zabronione.

PFS (Perfect Forward Secrecy):

PFS jest obowiązkowe. Każda Child SA (ESP — Encapsulating Security Payload) negocjuje nowy klucz Diffie-Hellman niezależnie od IKE SA. Kompromitacja klucza jednej sesji nie wpływa na inne sesje ani na przeszłe/przyszłe sesje.

Rekeying:

Parametr	Wartość	Uzasadnienie
IKE SA lifetime	24h	Balance: security vs handshake overhead
Child SA lifetime	1h	Ograniczenie okna kompromitacji
Child SA byte limit	1 GB	Ograniczenie ilości danych na klucz
Rekey margin	10% TTL	Start rekeying przed wygaśnięciem
Rekey jitter	5%	Rozłożenie rekeying w czasie

Rekeying odbywa się transparentnie (make-before-break): nowa SA jest negocjowana zanim stara wygaśnie. Zero packet loss.

Dead Peer Detection (DPD):

DPD enabled: keepalive co 30s. Peer unresponsive po 120s → SA teardown → reconnect. DPD zapobiega „zombie” tunelom (SA istnieje, ale peer jest offline).

Hybrid PQC (przyszłość):

SYLION planuje migrację do hybrydowego IKEv2 z PQC (post-quantum cryptography): IKEv2 z klasycznym ECDH + ML-KEM (Kyber) jako dodatkowy DH exchange. Status: [R] (rekomendowany pilot), pełne wdrożenie po standaryzacji NIST (expected 2026–2027).

65.2 Wzorce mTLS — SPIFFE/SVID, rotacja certyfikatów

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect, Backend Developer Wpływ na baseline: Krytyczny Powiązane rozdziały: 55.3, 55.9, 66.3

mTLS (mutual TLS) jest obowiązkowy dla komunikacji service-to-service. Certyfikaty zarządzane przez SPIRE + Vault PKI.

Wzorzec:

[Service A] ↔ [Envoy Sidecar A] ←mTLS→ [Envoy Sidecar B] ↔ [Service B] ↓ ↓ [SPIRE Agent] [SPIRE Agent] ↓ ↓ [SPIRE Server / Vault PKI]

Service nie zarządza certyfikatami bezpośrednio — Envoy sidecar terminuje mTLS. Certyfikat dostarczany przez SPIRE Agent via SDS (Secret Discovery Service) API.

Rotacja certyfikatów:

SVID TTL: 1h. Renewal: co 30 min (50% TTL).

Rotacja transparentna: SPIRE Agent dostarcza nowy certyfikat do Envoy → Envoy hot-reloads → zero downtime.

Intermediate CA rotation: co 90 dni. SPIRE Server automatycznie przełącza na nowy intermediate. Trust bundle update propagowany do wszystkich agentów.

Root CA rotation: co 3–5 lat. Wymaga dual authorization, zaplanowanego okna, staged rollout (new root added to trust bundle → transition period → old root removed).

Failure modes:

SPIRE Server unavailable: SPIRE Agent cache'uje ostatni SVID. Workload działa do wygaśnięcia cached SVID (max 1h). Alert generowany natychmiast.

Certificate mismatch: Envoy odrzuca connection (TLS handshake failure). Alert + incident.

Clock skew: certyfikaty nieważne jeśli zegar hosta jest skewed >30s. NTP mandatory (chrony). Clock skew monitoring + alert.

65.3 Wzorce service mesh — sidecar proxy, mTLS everywhere

Status: [N] Normatywny Odbiorca: DevSecOps, Architekt, Backend Developer Wpływ na baseline: Wysoki Powiązane rozdziały: 65.2, 55.7, 63.9

SYLION stosuje service mesh (Envoy-based — Istio lub custom control plane) dla wszystkich komunikacji wewnętrznych (Zone 3, 4, 5).

Sidecar pattern:

Każdy pod/workload posiada Envoy sidecar proxy. Cały ruch sieciowy przechodzi przez sidecar. Sidecar odpowiada za: 1. mTLS termination/origination. 2.

Authorization policy enforcement (OPA integration). 3. Observability (metrics, logs, traces — OpenTelemetry). 4. Traffic management (retry, circuit breaker, timeout).

5. Rate limiting (local + global).

STRICT mTLS:

Mesh-wide mTLS w trybie STRICT — brak plaintext communication. Peer authentication mode: STRICT (reject non-mTLS). PERMISSIVE dozwolony wyłącznie podczas migracji (max 7 dni).

Authorization policies:

```
apiVersion: security.istio.io/v1 kind: AuthorizationPolicy metadata: name: session-broker-policy spec: selector: matchLabels: app: session-broker rules: - from: - source: principals: ["spiffe://syllion.local/zone2/g1-gateway"] to: - operation: methods: ["POST"] paths: ["/v2/sessions*"] - from: - source: principals: ["spiffe://syllion.local/zone3/policy-engine"] to: - operation: methods: ["GET"] paths: ["/v2/sessions*"]
```

Observability:

Envoy emituje metryki (Prometheus), logi dostępu (JSON → log pipeline), traces (OpenTelemetry → Jaeger/Tempo). Dashboard: per-service latency, error rate, throughput, mTLS adoption rate (must be 100%).

65.4 Brokered access — brak bezpośredniego dostępu, zawsze przez brokera

Status: [N] Normatywny Odbiorca: Architekt, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 63.3, 64.6, 62.4

Brokered access oznacza, że żaden użytkownik/terminal nie ma bezpośredniego połączenia do workloadu. Cała komunikacja przechodzi przez session broker (Zone 2).

Dlaczego brokered access:

Single point of policy enforcement: broker weryfikuje autoryzację, stosuje polityki (timeout, clipboard, print), monitoruje sesję.

No direct network path: endpoint (Zone 0) nie zna IP workloadu (Zone 3). DNS resolution zablokowany.

Session lifecycle management: broker zarządza cyklem życia sesji — tworzenie, wstrzymywanie, terminacja.

Audit: broker loguje metadane sesji (kto, kiedy, ile trwała, ile danych).

Implementacja:

Zone 0 → Zone 1 → Zone 2 (G1: session negotiation) → Zone 2 (G2: pixel/media stream) → Zone 3 (workload).

G1 sprawdza: czy użytkownik jest uwierzytelniony, czy ma aktywne uprawnienie do danego workloadu, czy polityka pozwala na sesję w tym czasie.

G2 nawiązuje strumień do workloadu i relay'uje do klienta.

Klient nigdy nie widzi IP workloadu. Workload nigdy nie widzi IP klienta (broker maskuje).

Wyjątki:

Brak wyjątków. Każdy dostęp do workloadu przechodzi przez broker. Admin access do Zone 3 (maintenance) = dedykowany admin broker (bastion-as-a-service) z Four-Eyes.

65.5 App publishing — server-side rendering, pixel streaming

Status: [N] Normatywny Odbiorca: Architekt, Frontend Developer, UX Wpływ na baseline: Wysoki Powiązane rozdziały: 63.4, 64.4, 65.4

SYLION stosuje model server-side rendering (app publishing) zamiast tradycyjnego client-server:

Model:

Aplikacja działa w microVM (Zone 3).

Rendering (GUI) odbywa się server-side.

Pixel stream (skompresowane ramki ekranu) przesyłany do klienta przez broker (Zone 2).

Klient (thin client) wyświetla pixel stream i wysyła input events (klawiatura, mysz, touch).

Brak kodu aplikacji na kliencie. Brak danych na kliencie.

Protokoły:

Remote desktop: oparty na Guacamole/RDP/VNC (encapsulated w HTTPS WebSocket).

App streaming: dedykowany protokół pixel streaming (H.264/H.265 encoded).

Latency optimization: adaptive quality (bitrate dostosowywany do bandwidth), keyframe optimization, input prediction.

- Bezpieczeństwo:
- Dane nigdy nie opuszczają Zone 3 w formie strukturalnej — wyłącznie jako piksele.
- Copy/paste, file transfer, printing — kontrolowane przez politykę (domyślnie zablokowane).
- Screen recording — opcjonalne (per-policy), encrypted, audit-logged.
- Micro-watermarking [O] — steganograficzne znaczniki w pixel stream.

65.6 Media plane — SFU, SRTP/DTLS

- Status: [N] Normatywny Odbiorca: Architekt, Backend Developer, Security Architect Wpływ na baseline: Wysoki Powiązane rozdziały: 63.3, 64.6, 65.4
- Media plane obsługuje komunikację audio/video w SYLION (konferencje, rozmowy).
- Architektura:
- SFU (Selective Forwarding Unit): relay serwer, który przekazuje strumienie media między uczestnikami bez miksowania. SFU widzi zaszyfrowane strumienie (SFrame).
- SRTP (Secure Real-time Transport Protocol): transport encryption dla media.
- DTLS (Datagram Transport Layer Security): key exchange dla SRTP.
- E2EE dla media (Blind Broker):
- SFrame (RFC 9605) / WebRTC Insertable Streams: uczestnicy szyfrują media end-to-end kluczem sesji. SFU (G2) widzi wyłącznie ciphertext — nie może odszyfrować audio/video. Zwalidowane i normatywne.
- Key management:
- Per-conference key: generowany przez inicjatora, dystrybuowany do uczestników via E2EE channel (MLS — Message Layer Security lub Matrix Megolm).
- Key rotation: przy każdej zmianie uczestników (join/leave) — forward/backward secrecy.
- Key exchange: via signaling channel (Matrix), zaszyfrowany end-to-end.
- Ograniczenia:
- SFrame zwalidowany wyłącznie dla audio/video. Nie dotyczy kanału remote desktop (patrz 64.6).
- Duże konferencje (>50 uczestników): SFrame overhead może wpływać na latencję. Limit rekomendowany: 50 uczestników per-konferencja.

65.7 API auth patterns — OAuth2+mTLS, token binding

- Status: [N] Normatywny Odbiorca: Backend Developer, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 55.1, 55.4, 53.7
- OAuth2 + mTLS (dla service-to-service):
- Rekomendowany pattern dla wewnętrznych API calls: mTLS zapewnia authentication, OAuth2 Client Credentials zapewnia authorization (scope-based). Token jest powiązany z certyfikatem mTLS (certificate-bound tokens — RFC 8705). Nawet jeśli token wycieknie, nie można go użyć bez odpowiedniego certyfikatu.
- Token binding (DPoP):
- Dla klientów interaktywnych (tier STATE): DPoP (RFC 9449) — token powiązany z kluczem kryptograficznym klienta. Proof-of-possession eliminuje ryzyko token theft (token jest bezużyteczny bez klucza prywatnego klienta).
- Pattern per typ klienta:

Klient	Auth pattern	Token type
Admin panel (browser)	OAuth2 PKCE + session cookie	Access JWT + refresh (HttpOnly cookie)
Thin client (desktop)	OAuth2 PKCE + DPoP (STATE)	Access JWT (DPoP-bound)
Service internal	mTLS + Client Credentials	Certificate-bound JWT
Partner external	OAuth2 Client Credentials + API key	Access JWT
Webhook consumer	HMAC signature	N/A (request signing)

65.8 Secret zero problem i rozwiązanie — Vault Agent, IAM-based secret delivery

- Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 66.1, 66.7, 58.6
- Problem:
- Secret zero to fundamentalny problem bootstrapping: aby pobrać sekrety z Vault, serwis potrzebuje credentials do Vault. Skąd bierze te credentials?
- Rozwiązanie SYLION:
- Wielowarstwowe podejście eliminujące hardcoded secrets:
- Kubernetes Auth: workload w Kubernetes uwierzytelnia się do Vault za pomocą service account JWT tokenu (Kubernetes auth method). Token jest automatycznie mountowany przez Kubernetes (projected volume). Vault weryfikuje token z Kubernetes API.
- SPIRE-based Auth: SPIRE Agent dostarcza SVID (X.509 cert) do workloadu. Workload używa SVID do uwierzytelnienia w Vault (cert auth method). Eliminuje zależność od Kubernetes API.
- Cloud IAM Auth: w deployment cloud: workload używa cloud IAM identity (AWS IRSA, Azure Managed Identity, GCP Workload Identity) do uwierzytelnienia w Vault.
- Vault Agent sidecar:

Vault Agent deployowany jako sidecar do każdego poda: - Automatycznie uwierzytelnia się do Vault (Kubernetes/SPIRE/IAM auth). - Pobiera sekrety i renderuje do shared volume (tmpfs — memory-only, nie on-disk). - Automatycznie odświeża sekrety przed wygaśnięciem (lease renewal). - Application czyta sekrety z pliku na tmpfs — nie musi znać Vault API.

Zakaz:

Hardcoded secrets w kodzie: P0 defect.

Secrets w environment variables: dozwolone wyłącznie jeśli zainicjowane przez Vault Agent (nie przez ConfigMap/Secret Kubernetes).

Secrets w git: wykrywane przez pre-commit hooks (gitLeaks) → commit rejected.

65.9 Key establishment patterns — IKEv2, hybrid PQC

Status: [N] Normatywny (IKEv2) / [R] Rekomendowany (PQC) Odbiorca: Security Architect, Cryptography Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 65.1, 66.1, 66.4

IKEv2 Key Establishment (current):

ECDH P-384 lub X25519 jako DH group. Algorytmy negocjowane w IKE_SA_INIT. SYLION wymaga: - Encryption: AES-256-GCM - PRF: HMAC-SHA-384 - DH: ECDH P-384 (preferred) lub X25519 - Auth: RSA-4096 lub ECDSA P-384 (certificate-based)

Hybrid PQC Key Establishment (planned [R]):

Przygotowanie na quantum computing: hybrydowe podejście łączące klasyczną kryptografię z post-quantum:

IKEv2: ECDH P-384 + ML-KEM-1024 (Kyber-1024) jako double encapsulation.

TLS 1.3: X25519 + ML-KEM-768 (hybrid key exchange).

Podpisy: ECDSA P-384 + ML-DSA-87 (Dilithium) — dual signatures.

Hybrydowe podejście zapewnia: jeśli jeden algorytm zostanie złamany (klasyczny przez quantum computer, PQC przez nowy atak kryptoanalityczny), drugi nadal chroni.

Timeline migracji PQC:

2026 Q2: pilot — hybrydowe TLS na API Gateway (opt-in).

2026 Q4: hybrydowe IKEv2 na IPsec Gateway (opt-in).

2027: NIST finalizacja standardów PQC.

2027 Q2: hybrydowe TLS domyślne dla nowych deploymentów.

2028: full migration — klasyczne-only deprecated.

CNSA 2.0 alignment:

NSA CNSA 2.0 (Commercial National Security Algorithm Suite) wymaga migracji do PQC do 2030 (software) i 2033 (firmware/hardware). SYLION timeline jest szybszy (2027–2028) dla proactive posture.

65.10 Bezpieczne wzorce retry/backoff

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps Wpływ na baseline: Wysoki Powiązane rozdziały: 56.8, 56.7, 67.2

Bezpieczne retry obejmuje nie tylko wydajność (patrz 56.8), ale również aspekty bezpieczeństwa:

Security-aware retry:

Nie retry’uj 401/403: odpowiedzi uwierzytelniające/autoryzacyjne nie powinny być retry’owane automatycznie (mogą wskazywać na revoked access, nie transient error). Wyjątek: token refresh workflow.

Nie retry’uj po security event: jeśli serwis odpowiada nagłówkiem X-Sylion-Security-Event: true, klient nie powinien retry’ować — request mógł wyzwolić security alert.

Retry budget per-token: max retries per-token per-endpoint — ochrona przed amplifikacją ataku (stolen token → retry loop → DDoS).

Jitter obowiązkowy: full jitter (nie exponential-only) — zapobieganie synchronizacji klientów (thundering herd).

Circuit breaker integration: retry respektuje circuit breaker state. Open circuit → natychmiastowy fail, brak retries.

Logging:

Każdy retry jest logowany z kontekstem (original request ID, retry attempt number, reason). Agregacja retry rate per-service → dashboard. Anomalnie wysoki retry rate → alert (potencjalny incident lub degradation).

Rozdział 66. Zarządzanie tajemnicami i rotacja kluczy

66.1 Klasyfikacja tajemnic — od ROOT CA keys do operator secrets

Status: [N] Normatywny Odbiorca: Security Architect, CISO, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 58.6, 62.3, 66.2

SYLION definiuje hierarchiczną klasyfikację tajemnic, od najwrażliwszych do najmniej wrażliwych:

Tier	Tajemnica	Przechowywanie	Dostęp	Rotacja
T0 (ROOT)	Root CA private key	HSM (FIPS 140-3 L3)	Dual control, physical presence	3–5 lat

T1 (INFRA)	Intermediate CA keys	Vault (HSM-backed)	Platform Admin + Security	6–12 miesięcy
T1 (INFRA)	Vault unseal keys / recovery keys	HSM / Shamir shares (offline)	Emergency only, dual control	When compromised
T2 (SERVICE)	Service certificates (SVID)	SPIRE Agent (memory)	Automatic (SPIRE)	1h TTL
T2 (SERVICE)	Database credentials	Vault (dynamic)	Service identity (auto)	1h TTL
T2 (SERVICE)	JWT signing keys	Vault Transit / HSM	Auth service	30 dni
T3 (SESSION)	Session tokens (JWT)	Client memory	Bearer	15 min TTL
T3 (SESSION)	E2EE session keys	In-memory (workload)	Session participants	Per-session, PFS
T4 (INTEGRATION)	API keys (partner)	Vault KV (hashed in DB)	Partner (scoped)	365 dni max
T4 (INTEGRATION)	Webhook secrets	Vault KV	Service + partner	90 dni
T5 (OPERATOR)	Operator BYO-KMS keys	Operator-managed HSM/KMS	Operator only	Operator policy
T5 (OPERATOR)	Operator encryption keys	Vault (per-operator namespace)	Operator workloads	90 dni

Zasada: im wyższy tier (T0 = najwyższy), tym bardziej restrykcyjne kontrole dostępu, rzadsza rotacja (bo procedura jest bardziej złożona), i wyższe wymagania backup/recovery.

66.2 Cykl życia tajemnic — generation → distribution → use → rotation → revocation → destruction

Status: [N] Normatywny Odbiorca: Security Architect, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 66.1, 66.3, 66.5

Generation:

Tajemnice generowane przez CSPRNG (Cryptographically Secure Pseudo-Random Number Generator).

Klucze kryptograficzne: generowane w HSM (T0, T1) lub Vault Transit (T2+).

Hasła/tokeny: generowane przez Vault (dynamic secrets).

Zakaz: ręczne generowanie tajemnic, wybieranie haseł, reuse.

Distribution:

T0: nigdy nie opuszcza HSM (operacje kryptograficzne wykonywane w HSM).

T1: dostarczone do Vault (encrypted transit, HSM-to-Vault).

T2: dostarczane przez Vault Agent / SPIRE Agent do workloadu (tmpfs, memory-only).

T3: wydawane przez Auth Server → klient (HTTPS).

T4: wydawane przez Admin Portal → partner (one-time display).

Use:

Tajemnice używane wyłącznie do zamierzonego celu (key usage constraints).

Tajemnice nie logowane (nigdy w plain text w logach, traces, error messages).

Tajemnice nie w pamięci dłużej niż konieczne (zerowanie po użyciu — secure memory wiping).

Rotation:

Patrz 66.4.

Revocation:

Patrz 66.5.

Destruction:

Kryptograficzne usunięcie: nadpisanie losowymi danymi (minimum 3 passes — DoD 5220.22-M).

HSM: zeroization command.

Vault: vault kv destroy (permanent delete z garbage collection).

Memory: memset_s / explicit_bzero (compiler-safe zeroing).

Physical media: degaussing, physical destruction (dla nośników wycofanych z produkcji).

66.3 Proces wydawania per-typ tajemnicy

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect Wpływ na baseline: Wysoki Powiązane rozdziały: 66.1, 66.2, 58.6

Root CA (T0):

Ceremonia generacji klucza: 1. Air-gapped workstation (no network). 2. 3 osoby obecne (CISO, Security Architect, witness). 3. HSM initialized (FIPS 140-3 L3). 4. Root key generated in HSM (never exported). 5. Root certificate self-signed (validity: 10 lat). 6. Root cert published to trust stores. 7. Ceremonia udokumentowana, podpisana, archiwizowana.

Intermediate CA (T1):

CSR generated in Vault PKI.

CSR signed by Root CA (HSM operation — ceremony, 2 osoby).

Intermediate cert imported to Vault PKI.

Intermediate cert published to trust stores.

Service certificates (T2):

SPIRE Agent requests SVID from SPIRE Server.

SPIRE Server verifies workload attestation.

SPIRE Server issues X.509 SVID (signed by Intermediate CA via Vault PKI).

SVID delivered to workload via SDS API.

Automatic renewal at 50% TTL.

Dynamic database credentials (T2):

Vault Database Secrets Engine configured for PostgreSQL.

Service requests credentials: vault read database/creds/session-service-role.

Vault creates temporary role in PostgreSQL (TTL 1h).

Credentials returned to service (via Vault Agent → tmpfs).

On expiry: Vault drops the PostgreSQL role.

JWT signing keys (T2):

Key pair generated in Vault Transit or HSM.

Public key published to JWKS endpoint (/oauth2/jwks).

Auth Service signs JWTs via Vault Transit API (key never leaves Vault/HSM).

Rotation: new key generated, old key retained in JWKS for overlap (48h).

API keys (T4):

Partner requests key via Admin Portal.

System generates 256-bit random key.

SHA-256 hash stored in database. Key displayed once.

Key bound to: partner ID, IP whitelist, scope, TTL.

66.4 Harmonogramy i triggerzy rotacji

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 66.1, 66.3, 66.5

Rotacja planowana (scheduled):

Tajemnica	Częstotliwość	Mechanizm
Root CA	3–5 lat	Ceremonia (manual, HSM)
Intermediate CA	6–12 miesięcy	Semi-automated (Vault PKI)
JWT signing key	30 dni	Automated (Vault Transit)
Service cert (SVID)	1h	Automated (SPIRE)
Database credentials	1h	Automated (Vault Dynamic Secrets)
Webhook secrets	90 dni	Automated (Vault KV + API notification)
API keys (partner)	365 dni	Manual (partner requests new key)
Operator encryption keys	90 dni	Automated (Vault)

Rotacja wyzwolona (event-triggered):

Trigger	Akcja
CVE w algorytmie kryptograficznym	Emergency rotation all affected keys
Podejrzenie kompromitacji klucza	Immediate revocation + rotation
Zmiana personelu z dostępem do T0/T1	Rotation ceremony within 7 days
Cert expiry approaching (14 days)	Alert + auto-rotation (T2+)
Failed attestation	Revoke affected SVIDs + re-issue
Incident (security breach)	Bulk rotation: all T2+ in affected zone

Monitoring:

Dashboard: secret age, time-to-expiry, rotation success/failure rate. Alert: secret older than 2× planned rotation interval (missed rotation). Compliance report: evidence that all secrets are rotated per-schedule.

66.5 Revocation — natychmiastowa, planowana, masowa

Status: [N] Normatywny Odbiorca: Security Architect, SOC, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 66.4, 66.6, 55.4

Natychmiastowa revocation:

Triggered by: confirmed compromise, security incident, malicious insider detection.

Mechanizmy: - JWT: add jti to revocation list (Redis-based, TTL = token remaining lifetime). All services check revocation list before accepting JWT. - Certificate: CRL (Certificate Revocation List) published by Vault PKI. OCSP stapling for real-time verification. Envoy checks OCSP/CRL. - API key: mark as revoked in database. API Gateway checks on every request. - Vault lease: vault lease revoke — immediately drops dynamic credentials (database roles, cloud IAM).

Planowana revocation:

Part of rotation — old key/cert revoked after overlap period. Graceful: consumers switch to new key, then old key revoked.

Masowa revocation (bulk):

Scenariusz: kompromitacja Intermediate CA → all certificates issued by that CA must be revoked.

Procedura: 1. SOC identifies scope of compromise. 2. Emergency rotation: new Intermediate CA key generated and signed by Root CA. 3. SPIRE Server configured with new Intermediate CA. 4. All SVIDs automatically re-issued within 1h (next rotation cycle). 5. Old Intermediate CA added to CRL. 6. Verification: monitoring confirms 0 connections using old certs. 7. Post-incident review.

Czas revocation:

Typ tajemnicy	Target revocation time
JWT (access token)	< 1 min (revocation list)
Certificate (service)	<5 min (OCSP update + SVID re-issue)
Database credentials	< 1 min (Vault lease revoke)
API key	< 1 min (database update + cache invalidation)
Intermediate CA	<1h (CRL publish + all SVIDs re-issued)

66.6 Break-glass secrets — procedura, audyt, re-seal

Status: [N] Normatywny Odbiorca: CISO, Platform Admin, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.3, 66.1, 64.13

Break-glass to procedura awaryjnego dostępu do najważniejszych zasobów (Vault root, management plane) w sytuacji, gdy normalna ścieżka autoryzacji jest niedostępna (np. wszyscy administratorzy niedostępni, systemy auth down).

Break-glass credentials:

Vault recovery keys: Shamir Secret Sharing (5 shares, threshold 3). Shares przechowywane w fizycznych sejfach w różnych lokalizacjach, przypisane do różnych osób.

Emergency admin account: disabled by default. Activation wymaga 3-of-5 Shamir shares.

TOTP emergency codes: pre-generated, printed, sealed envelope w sejfie.

Procedura break-glass:

Justification: osoba wywołająca dokumentuje przyczynę (incydent ID, opis).

Share collection: minimum 3 z 5 osób dostarcza Shamir shares (fizycznie lub zaszyfrowanym kanałem).

Unsealing: Vault unsealed z 3 shares.

Emergency access: emergency admin account activated. TTL: 2h (auto-disable).

Operations: wykonanie niezbędnych operacji (recovery, rotation, repair).

Re-seal: po zakończeniu operacji — Vault re-sealed. Emergency account disabled.

Audit: pełen log operacji. CISO notified immediately. Post-incident review w ciągu 24h.

Credential rotation: all secrets potentially accessed during break-glass are rotated.

Testowanie:

Break-glass procedure testowana co 6 miesięcy (tabletop exercise). Pełny break-glass drill co 12 miesięcy (actual Vault unseal → reseat w controlled environment).

66.7 Minimalizacja ekspozycji tajemnic — short TTL, just-in-time, memory-only

Status: [N] Normatywny Odbiorca: DevSecOps, Backend Developer Wpływ na baseline: Wysoki Powiązane rozdziały: 66.1, 65.8, 58.6

Short TTL:

Tajemnice mają najkrótszy praktyczny TTL: - Service certs: 1h (nie days/months). - Database creds: 1h (nie permanent). - Access tokens: 15 min. - Sesje: timeout per-policy.

Krótki TTL minimalizuje okno kompromitacji — skradziony secret staje się bezużyteczny po TTL.

Just-in-time delivery:

Sekrety dostarczane do workloadu tuż przed użyciem (not at deployment time). Vault Agent fetches secret → renders to tmpfs → application reads. Brak pre-provisioned secrets.

Memory-only:

Sekrety nigdy nie dotykają dysku: - Vault Agent renders to tmpfs (RAM-backed filesystem). - Application reads from tmpfs. - Kernel memory: secure wipe after use (explicit_bzero). - Swap disabled lub encrypted (prevent swap-out of secrets). - Core dumps disabled dla procesów z secrets (setrlimit RLIMIT_CORE 0).

66.8 Tajemnice w CI/CD — brak secrets w kodzie, integracja Vault, ephemeral credentials

Status: [N] Normatywny Odbiorca: DevSecOps, Backend Developer Wpływ na baseline: Krytyczny Powiązane rozdziały: 69.7, 66.7, 58.6

Reguły:

Zero secrets in code: gitleaks pre-commit hook na każdym repozytorium. Commit z secret → rejected.

Zero secrets in CI config: brak hardcoded secrets w .github/workflows, .gitlab-ci.yml, Jenkinsfile. Secrets referenced by name, delivered at runtime.

Vault integration: CI runner uwiarytelnia się do Vault (JWT auth method — CI JWT token → Vault policy → scoped secrets).

Ephemeral credentials: CI runner otrzymuje krótkotrwałe credentials (TTL = pipeline execution time + buffer). Po zakończeniu pipeline → credentials revoked.

Ephemeral runners: CI runners są ephemeral (nowy runner per-job). Brak persistent state — secret nie może przetrwać między pipeline’ami.

Signing in CI:

Podpisywanie artefaktów (container images, Helm charts) odbywa się za pomocą Vault Transit (signing key w Vault, private key never exported). CI runner wysyła digest do Vault → Vault zwraca podpis.

66.9 Tajemnice w runtime — env vars vs mounted files vs Vault Agent

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps Wpływ na baseline: Wysoki Powiązane rozdziały: 66.7, 65.8, 68.3

Porównanie metod:

Metoda	Security	Usability	Rekomendacja SYLION
Environment variables	❌ Widoczne w /proc, process listing, crash dumps	✅ Proste	⚠️ Dozwolone wyłącznie jeśli injected by Vault Agent
Mounted files (tmpfs)	✅ RAM-only, permissions-controlled, rotatable	✅ Standard	✅ Preferowane
Vault Agent sidecar	✅ Automatic renewal, memory-only	✅ Transparent	✅ Obowiązkowe
Direct Vault API calls	✅ On-demand, no file on disk	⚠️ Wymaga Vault o D ✅ client	zwolone (advanced use cases)
Kubernetes Secrets	❌ Base64-encoded (not encrypted by default), etcd exposure	✅ Native	❌ Zabronione (use Vault instead)

Standard SYLION:

Vault Agent sidecar → renders secrets to tmpfs → application reads file. Auto-renewal enabled. Application nie musi wiedzieć o Vault.

Wyjątek: Kubernetes Secrets dozwolone wyłącznie dla non-sensitive config (feature flags, non-secret parameters). Nigdy dla passwords, tokens, keys, certificates.

66.10 Tajemnice w backupach — szyfrowane, oddzielna hierarchia kluczy

Status: [N] Normatywny Odbiorca: SRE, Security Architect, DBA Wpływ na baseline: Krytyczny Powiązane rozdziały: 58.5, 66.1, 64.11

Backupy zawierające tajemnice (Vault snapshots, database dumps z encrypted columns) muszą być chronione osobną hierarchią kluczy.

Hierarchia:

[Backup Master Key (BMK)] — stored in HSM or separate KMS — [Backup Encryption Key (BEK)] — per-backup, generated at backup time — [Backup data] — encrypted with BEK

BMK szyfruje BEK (envelope encryption). BMK przechowywany w HSM/KMS — oddzielnym od operational Vault. Kompromitacja operational Vault nie daje dostępu do backupów (i odwrotnie).

Reguły:

Backupy zawsze szyfrowane (AES-256-GCM).

Klucz szyfrowania backupu (BEK) rotowany per-backup (ephemeral).

BMK rotowany co 12 miesięcy.

Backup verification: monthly test restore (do isolated environment, verify decryption, verify data integrity).

Backup access: logged, dual authorization for restore.

Backup retention: per-policy (7 dni daily, 4 tygodnie weekly, 12 miesięcy monthly).

Backup deletion: secure deletion (crypto-shredding — delete BEK → backup unreadable).

66.11 Audyt operacji na tajemnicach

Status: [N] Normatywny Odbiorca: SOC, Compliance, Auditor Wpływ na baseline: Krytyczny Powiązane rozdziały: 58.4, 62.8, 66.2

Każda operacja na tajemnicy jest logowana w audit log:

Logowane operacje:

Operacja	Logowane dane
Read	Who, what path, when, source IP, result
Create	Who, what path, when, metadata (no value!)

Update	Who, what path, when, version change
Delete	Who, what path, when, Four-Eyes approver
Rotate	Who, what path, old version → new version
Revoke	Who, what path, when, reason
List	Who, what path prefix, when
Break-glass access	Full detail (who, shares used, operations, duration)

Wartości tajemnic NIGDY nie są logowane. Audit log zawiera metadata o operacji, nie wartość tajemnicy.

Alerting:

Read of T0/T1 secret: immediate alert to CISO.

Unusual volume of reads (>10× baseline): alert to SOC.

Failed access attempts (>5/min from one source): alert + temporary lockout.

Break-glass activation: immediate alert to all stakeholders.

Compliance report:

Monthly report: all secret operations, rotation compliance (% secrets rotated on schedule), anomalies detected, incidents.

Rozdział 67. Ochrona przed atakami sieciowymi i aplikacyjnymi

Ochrona przed atakami sieciowymi i aplikacyjnymi

67.1 Enumeracja i rekonesans

Status: [N] Normatywny Odbiorca: SOC, Security Architect, DevSecOps Wpływ na baseline: Wysoki Powiązane rozdziały: 64.2, 63.2, 62.4

Opis ataku: Atakujący skanuje infrastrukturę SYLION w celu identyfikacji usług, wersji oprogramowania, otwartych portów i potencjalnych wektorów ataku. Techniki: port scanning (nmap), DNS enumeration, banner grabbing, directory brute force, Google dorking.

Mitygacje SYLION: 1. Minimalna ekspozycja: wyłącznie API Gateway (Zone 1) eksponowany na internet. Wszystkie inne komponenty niewidoczne. 2. Brak bannerów: serwery nie ujawniają wersji (Server header usunięty, X-Powered-By usunięty). 3. Rate limiting na probes: port scan detection (>50 SYN/s z jednego IP) → automatic block (30 min). 4. DNS hardening: brak wildcard DNS, split-horizon DNS (internal vs external views), DNSSEC. 5. Directory brute force protection: 404 dla nieistniejących endpointów (nie 403 — nie ujawnia istnienia zasobów).

Detekcja: IDS/IPS na Zone 1 (Suricata/Snort rules), API Gateway logs (anomalous patterns), threat intelligence feeds.

Ryzyko rezydualne: Atakujący ustali istnienie API Gateway i podstawowy profil TLS. Nie uzyska informacji o wewnętrznej architekturze.

67.2 DDoS — wolumetryczny i warstwa aplikacyjna

Status: [N] Normatywny Odbiorca: SRE, Network Engineer, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 56.1, 56.3, 63.2

Opis ataku: Atak odmowy usługi — wolumetryczny (L3/L4: SYN flood, UDP amplification, DNS amplification) lub aplikacyjny (L7: HTTP flood, slowloris, resource-expensive queries).

Mitygacje SYLION: 1. L3/L4 DDoS: CDN/DDoS protection (Cloudflare, AWS Shield, Akamai) przed Zone 1. Absorpcja volumetric traffic. 2. L7 DDoS: rate limiting (patrz 56.1), bot detection (behavioral analysis, CAPTCHA), connection limits (56.2). 3. Slowloris: request header timeout (10s), request body timeout (30s). 4. Auto-scaling: Zone 1 (API Gateway) auto-scales pod obciążeniem. Priority lanes zapewniają dostępność security operations (56.3). 5. Geo-blocking: opcjonalne ograniczenie ruchu do dozwolonych regionów. 6. Blackhole routing: w ostateczności — null route atakowanego IP/prefix (coordination z ISP).

Detekcja: traffic anomaly detection (VictoriaMetrics), CDN alerts, bandwidth monitoring, latency spike alerts.

Ryzyko rezydualne: Wystarczająco duży DDoS (nation-state) może degradować dostępność pomimo CDN. Mitygacja: multi-CDN, anycast, geographic distribution.

67.3 Man-in-the-Middle (MITM)

Status: [N] Normatywny Odbiorca: Security Architect, Network Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 65.1, 65.2, 64.5

Opis ataku: Atakujący wstawia się między dwie strony komunikacji, przechwytyjąc i potencjalnie modyfikując ruch.

Mitygacje SYLION: 1. IPsec IKEv2: certificate-based authentication eliminuje MITM na warstwie transportu (Zone 0 → Zone 1). 2. mTLS (SPIFFE): certificate-based mutual authentication eliminuje MITM wewnętrznie. 3. Certificate pinning: klient pinuje intermediate CA — nie akceptuje certyfikatów z innej CA. 4. HSTS: HTTP Strict Transport Security — przeglądarka nie pozwala na HTTP downgrade. 5. E2EE: nawet jeśli MITM uda się na warstwie transportu (np. kompromitacja certyfikatu), E2EE (SFrame, Matrix Megolm) chroni treść komunikacji.

Detekcja: certificate transparency monitoring (CT logs), unexpected cert changes, TLS fingerprint anomalies.

Ryzyko rezydualne: Kompromitacja Intermediate CA → valid MITM certs. Mitygacja: CT monitoring, short cert TTL (1h SVID), cert pinning.

67.4 Ataki na credentials — brute force, stuffing, phishing (FIDO2 eliminuje phishing)

Status: [N] Normatywny Odbiorca: SOC, Security Architect, Identity Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 55.1, 55.2, 63.1

Opis ataku: Próby odgadnięcia lub kradzieży credentials: brute force (próby wielu haseł), credential stuffing (użycie credentials z innego wycieku), phishing (fałszywa strona logowania).

Mitygacje SYLION: 1. FIDO2/WebAuthn: primary authentication. FIDO2 jest phishing-resistant by design — klucz prywatny powiązany z origin (domain), fałszywa strona nie otrzyma valid assertion. Eliminuje phishing całkowicie. 2. Rate limiting na auth: max 30 req/min per IP na /oauth2/token (patrz 56.1). 3. Account lockout: po 10 failed attempts → account locked na 15 min. Po 30 → permanent lock (manual unlock). 4. Credential stuffing detection: anomaly detection (wiele kont z jednego IP, known-breach correlation). 5. No passwords (ideal): dla tier STATE — FIDO2-only, brak hasła. Dla STANDARD/PRO — hasło + TOTP jako fallback (FIDO2 preferred). 6. Breached password check: przy ustawianiu hasła — sprawdzenie w HaveIBeenPwned (k-anonymity model, hash prefix query).

Detekcja: auth failure rate monitoring, geographic anomalies (login from unusual country), device fingerprint changes.

Ryzyko rezydualne: Targeted social engineering (nie phishing, ale np. impersonacja support) — mitygowane przez procedury weryfikacji tożsamości, no-password operations for critical actions.

67.5 Session hijacking

Status: [N] Normatywny Odbiorca: Backend Developer, Security Architect Wpływ na baseline: Wysoki Powiązane rozdziały: 55.4, 65.7, 52.3

Opis ataku: Kradzież session tokenu (JWT/cookie) i użycie go do przejęcia sesji użytkownika.

Mitygacje SYLION: 1. Short TTL: access token 15 min — okno hijacking ograniczone. 2. Token binding (DPoP): token powiązany z kluczem klienta. Skradziony token bezużyteczny bez klucza. 3. HttpOnly, Secure, SameSite=Strict cookies: ochrona przed XSS-based token theft. 4. Fingerprinting: token powiązany z fingerprint klienta (IP hash, user-agent). Zmiana fingerprint → token odrzucony. 5. Refresh token rotation: jednorazowy refresh token. Użycie starego refresh token → revocation all tokens (reuse detection). 6. Session monitoring: anomaly detection (session z dwóch IP, session z nieznanego urządzenia).

Detekcja: concurrent session detection (ten sam token z różnych IP), refresh token reuse detection (automatic revocation).

Ryzyko rezydualne: Real-time token forwarding (atakujący na tym samym urządzeniu, np. RAT) — mitygowane przez FIDO2 (session creation wymaga FIDO2, nie wystarczy token alone).

67.6 API abuse

Status: [N] Normatywny Odbiorca: Backend Developer, SOC, DevSecOps Wpływ na baseline: Wysoki Powiązane rozdziały: 56.1, 55.7, 52.3

Opis ataku: Nadużycie API: data scraping, enumeration (IDOR), privilege escalation, rate limit evasion, API key abuse.

Mitygacje SYLION: 1. Rate limiting (multi-level: per-client, per-endpoint, per-tenant). 2. Authorization (OPA fine-grained policies — 55.7). 3. IDOR prevention: UUID v4 identifiers (nie sekwencyjne). Brak possibility of enumeration. 4. Scope enforcement: token scope sprawdzany per-request. Over-scoped tokens odrzucane. 5. Input validation: JSON Schema validation na API Gateway. Malformed requests odrzucone. 6. Pagination limits: max 200 items/page. Brak „get all” endpoint. 7. Behavioral analysis: ML-based anomaly detection na API usage patterns.

Detekcja: unusual API patterns (sequential ID probing, rapid enumeration of resources, high-volume data retrieval), rate limit violations, scope escalation attempts.

Ryzyko rezydualne: Sophisticated attacker z valid credentials może nadużyć API w ramach swoich uprawnień. Mitygacja: behavioral monitoring, audit log analysis.

67.7 SSRF, RCE, deserializacja

Status: [N] Normatywny Odbiorca: Backend Developer, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 52.7, 68.3, 69.1

SSRF (Server-Side Request Forgery):

Atakujący powoduje, że serwer wykonuje request do wewnętrznego zasobu.

Mitygacje: - Webhook URL validation: blokada adresów wewnętrznych (RFC 1918, loopback, link-local, metadata services 169.254.169.254). - Egress firewall: mikroserwisy nie mogą nawiązywać połączeń do arbitralnych adresów. - URL scheme whitelist: wyłącznie HTTPS. - DNS rebinding protection: resolve URL, check IP, then connect.

RCE (Remote Code Execution):

Atakujący uzyskuje wykonanie kodu na serwerze (np. Guacamole CVE-2024-35164).

Mitygacje: - MicroVM isolation (Firecracker) — RCE w microVM nie daje dostępu do hosta. - Seccomp + AppArmor — ograniczenie syscalls. - No shell access (no /bin/sh w production containers). - Input sanitization, parameterized queries, CDR for file uploads. - Patching + rebuild-first (62.7).

Deserializacja:

Atakujący wysyła malicious serialized object.

Mitygacje: - JSON-only (no Java serialization, no pickle). - JSON Schema validation before processing. - No generic deserialization (no Object.class deserialization w Java). - Protobuf: type-safe, no arbitrary code execution.

Detekcja: WAF rules (SSRF patterns, RCE payloads), runtime monitoring (unexpected process execution, network connections), SAST (deserializacja patterns).

67.8 Ataki na supply chain

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect, CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 69.1–69.11, 71.15

Opis ataku: Kompromitacja zależności, build tools, CI/CD pipeline, container images. Przykłady: xz-utils backdoor (CVE-2024-3094), SolarWinds.

Mitygacje SYLION: 1. SBOM: Software Bill of Materials dla każdego artefaktu (patrz 69.1). 2. SCA: ciągłe skanowanie zależności (69.2). 3. Dependency pinning: lockfiles z hash verification (69.3). 4. Artifact signing: cosign/Sigstore (69.4). 5. Provenance: SLSA v1.2 Level 3 (69.5). 6. Reproducible builds: deterministic outputs (69.6). 7. Pipeline hardening: ephemeral runners, no persistent credentials (69.7). 8. Approved registry: dependencies wyłącznie z approved registry (69.9). 9. Vendor assessment: security questionnaires for critical vendors (69.10).

Detekcja: SCA alerts (new CVE in dependency), provenance verification failure, unexpected changes in SBOM, build reproducibility check failure.

Ryzyko rezydualne: Sophisticated supply chain attack (0-day w widely-used library, compromised developer) — okno eksploatacji od momentu kompromitacji do wykrycia przez community.

67.9 Złośliwe załączniki — CDR jako primary control

Status: [N] Normatywny Odbiorca: Security Architect, SOC, Backend Developer Wpływ na baseline: Krytyczny Powiązane rozdziały: 58.5, 64.4, 71.5

Opis ataku: Atakujący przesyła malicious file (malware, exploit document, steganographic payload) przez komunikację SYLION.

CDR (Content Disarm and Reconstruct):

CDR jest primary control — nie antywirus (signature-based), ale dekonstrukcja i rekonstrukcja pliku:

Plik przesłany → staging (encrypted object store, Zone 3).

CDR engine (isolated, no network access) parsuje plik.

Elementy aktywne usuwane: macros (Office), JavaScript (PDF), embedded objects, OLE, DDE.

Plik rekonstruowany z bezpiecznych elementów (text, images, formatting).

Rekonstruowany plik dostarczany odbiorcy.

Oryginalny plik: quarantine (30 dni) lub usunięty.

Obsługiwane formaty:

Office (docx, xlsx, pptx), PDF, images (strip metadata, re-encode), archives (zip — recursive CDR), email (EML/MSG — CDR attachments).

Ograniczenia CDR:

Pliki z active content tracą makra (by design — makra to wektor ataku).

Plik po CDR może wyglądać inaczej (usunięte animacje, embedded objects).

Nieobsługiwane formaty: blocked by default (whitelist approach).

CDR nie gwarantuje 100% effectiveness (novel evasion techniques).

Detekcja: CDR logs (ile plików przetworzonych, ile zmodyfikowanych, ile quarantined), anomaly detection (unusual file types, high volume from one user).

67.10 Lateral movement — mikrosegmentacja jako primary control

Status: [N] Normatywny Odbiorca: Security Architect, Network Engineer, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 63.1, 63.9, 68.5

Opis ataku: Po kompromitacji jednego komponentu, atakujący próbuje poruszać się do innych komponentów (pivot).

Mitygacje SYLION: 1. Mikrosegmentacja: NetworkPolicy deny-all default. Explicit allow per-service pair. Atakujący z RCE w jednym mikroservisie nie może połączyć się z innymi (chyba że są na explicit allow list). 2. MicroVM isolation: workload w Firecracker — brak shared kernel z innymi workloadami. VM escape wymagany do lateral movement. 3. SPIFFE/mTLS: nawet jeśli atakujący jest w sieci, nie ma valid SVID — nie może uwierzytelnić się do innych serwisów. 4. Short-lived credentials: skompromitowane credentials wygasają w minutach/godzinach. 5. No shared admin credentials: każdy serwis ma dedykowane credentials (dynamic secrets z Vault).

Detekcja: unexpected network flows (connection attempts to non-allowed services), SPIFFE auth failures, service mesh telemetry anomalies.

Ryzyko rezydualne: Jeśli atakujący skompromituje serwis z szerokim dostępem (np. monitoring) — może mieć ścieżkę do wielu serwisów. Mitygacja: even monitoring services mają minimal access, read-only.

67.11 Exfiltracja — egress control + CDR + DLP

Status: [N] Normatywny Odbiorca: SOC, Security Architect, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.4, 64.10, 67.12

Opis ataku: Atakujący wyciąga dane z SYLION (database dump, file copy, covert channel).

Mitygacje SYLION: 1. Egress deny-default: workloady nie mają dostępu do internetu (domyślnie). Whitelist per-operator. 2. CDR na egress: pliki opuszczające sesję przechodzą CDR (strip metadata, sanitize). 3. DLP (Data Loss Prevention) [R]: opcjonalne reguły DLP skanujące zawartość wychodzących plików (regex patterns, named entity detection). Status [R] — rekomendowane, nie obowiązkowe. 4. Clipboard control: kopiuj/wklej z sesji zablokowane domyślnie. 5. Print control: drukowanie zablokowane domyślnie. 6. Bandwidth monitoring: anomalnie duży transfer (>X MB/session) → alert. 7. DNS exfiltration protection: DNS queries monitorowane, unusual patterns (long subdomains, high query rate) → block + alert.

Detekcja: egress traffic monitoring, DNS query analysis, bandwidth anomalies, file transfer logs.

Ryzyko rezydualne: Optical leak (fotografowanie ekranu) — patrz 64.10. Covert channels (steganografia w dozwolonym ruchu) — trudne do wykrycia, mitygowane przez bandwidth monitoring.

67.12 Insider exfiltration

Status: [N] Normatywny Odbiorca: CISO, SOC, HR Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.3, 64.10, 67.11

Opis ataku: Autoryzowany użytkownik/admin systematycznie wyciąga dane używając legalnego dostępu.

Mitygacje SYLION: 1. Behavioral analytics: baseline zachowań per-user. Anomalie: unusually large data access, access at unusual hours, access to rarely used resources. 2. Principle of least privilege: user widzi wyłącznie dane potrzebne do pracy. 3. Four-Eyes: destrukcyjne/export operations wymagają drugiej osoby. 4. Micro-watermarking [O]: identyfikacja source wycieku. 5. Session recording (opt-in): nagranie aktywności użytkownika. 6. Off-boarding procedure: natychmiastowa dezaktywacja + audit review przy rozstaniu z pracownikiem.

Detekcja: UEBA (User and Entity Behavior Analytics), access pattern analysis, export volume monitoring.

Ryzyko rezydualne: Powolna, niskopoziomowa exfiltracja (np. jedna strona dziennie, kopiowana ręcznie) — trudna do wykrycia technicznie. Mitygacja: procedury organizacyjne, NDA, background checks.

67.13 Kompromitacja brokera

Status: [N] Normatywny Odbiorca: Security Architect, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.6, 63.3, 71.6

Opis ataku: Atakujący uzyskuje RCE na session brokerze (Zone 2) — np. przez Guacamole CVE-2024-35164.

Mitygacje SYLION: Patrz 64.6 dla pełnej analizy. Kluczowe: 1. Sandboxing w microVM (Firecracker + SEV-SNP). 2. Horizontal scaling (kompromitacja jednego noda ≠ kompromitacja wszystkich). 3. Credential limitation (broker ma dostęp wyłącznie do session metadata). 4. Runtime monitoring (eBPF/Tetragon). 5. Blind broker dla audio/video (SFrame). Remote desktop: [E], bez blind broker guarantee. 6. Network isolation: broker nie ma dostępu do management plane (Zone 5).

Detekcja: unexpected process execution, unusual network connections, file system modifications, memory anomalies.

Ryzyko rezydualne: Aktywne sesje desktop na skompromitowanym nodzie mogą być przechwycone. Mitygacja: automatic session rotation (przeniesienie sesji na inny node), rapid detection + response.

67.14 Workload breakout — izolacja microVM, SEV-SNP

Status: [N] Normatywny Odbiorca: Security Architect, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.7, 68.4, 71.7

Opis ataku: Atakujący z kontrolą nad workloadem (microVM) próbuje uciec z izolacji i uzyskać dostęp do hosta lub innych workloadów.

Mitygacje SYLION: 1. Firecracker VMM: minimalny Virtual Machine Monitor (tylko ~50K LoC). Minimalna powierzchnia ataku vs QEMU (~1.4M LoC). 2. Jailer: Firecracker jailer — chroot + namespace + seccomp + cgroups. 3. SEV-SNP/TDX: pamięć VM szyfrowana — nawet host nie ma dostępu do plaintext. 4. No virtio-net direct: ograniczone virtio devices (block, net, vsock — minimum). 5. Network namespace: per-VM network namespace. VM-to-VM traffic zablokowany domyślnie. 6. Host hardening: CIS benchmark, minimal packages, immutable OS. 7. eBPF monitoring: Tetragon monitoruje syscalls VM process — unexpected syscalls (mount, ptrace, ioctl on host devices) → alert.

Detekcja: unexpected syscalls from VMM process, network anomalies from VM, resource consumption anomalies.

Ryzyko rezydualne: Firecracker VMM vulnerability (escape) — mitygowane przez minimalizm kodu, security audit, fuzzing. SEV-SNP bypass (CVE history) — patrz 64.7.

67.15 Cloud i hypervisor attacks

Status: [N] Normatywny Odbiorca: CISO, Security Architect, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.7, 64.8, 71.8

Opis ataku: Cloud provider (lub atakujący z dostępem do cloud infrastructure) próbuje uzyskać dostęp do danych SYLION.

Mitygacje SYLION: 1. SEV-SNP/TDX: pamięć VM szyfrowana (defense-in-depth, nie absolutna — patrz 64.7). 2. Encryption at-rest: wszystkie dane szyfrowane kluczem klienta (BYO-KMS dla STATE). Provider nie ma klucza. 3. IPsec/mTLS: provider widzi wyłącznie zaszyfrowany ruch sieciowy. 4. Attestation: weryfikacja integralności VM — provider nie może podłożyć zmodyfikowanego firmware. 5. Autonomous perimeter [A]: eliminacja cloud provider z trust boundary (STATE). 6. Multi-cloud readiness: architektura cloud-agnostic, możliwość migracji.

Detekcja: attestation failures, unexpected VM modifications, network anomalies (traffic to unexpected cloud endpoints).

Ryzyko rezydualne: Provider z fizycznym dostępem do hardware (cold boot, hardware implant, firmware modification) — SEV-SNP/TDX minimalizuje, ale nie eliminuje. Dla najwyższego bezpieczeństwa: autonomous perimeter (on-premises / sovereign cloud).

Rozdział 68. Runtime security i RSM

Runtime security i RSM

68.1 Cele ochrony runtime

Status: [N] Normatywny Odbiorca: Security Architect, DevSecOps, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.1, 67.14, 68.2

Runtime security (RSM — Runtime Security Monitoring) adresuje zagrożenia, które nie mogą być wykryte ani wyeliminowane w fazie budowania i deploymentu — ataki zero-day, eksploatacja luk w runtime, anomalne zachowania workloadów.

Cele:

Detect: wykrywanie anomalnych zachowań workloadów w czasie rzeczywistym (unexpected syscalls, network connections, file access).

Prevent: blokowanie znanych złośliwych wzorców (known-bad syscall sequences, network connections to C2 servers).

Contain: automatyczna izolacja skompromitowanego workloadu (network disconnect, pause, terminate).

Evidence: zbieranie danych forensycznych do analizy post-incident (syscall traces, network captures, process trees).

Zasada rebuild-first:

Runtime security jest komplementarna do rebuild-first (62.7). Wykrycie anomalii → natychmiastowe działanie (contain) → rebuild workloadu z known-good image → forensics na izolowanym artefakcie (snapshot skompromitowanej VM).

68.2 Hardening hosta — CIS benchmarks, minimalne pakiety, immutable OS

Status: [N] Normatywny Odbiorca: SRE, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 62.10, 68.3, 68.4

OS bazowy:

SYLION wymaga immutable OS na nodach roboczych: Flatcar Container Linux, Talos Linux lub RHCOS (Red Hat CoreOS). Immutable oznacza: - Read-only root filesystem. - Brak package manager w runtime (no apt, no yum). - Konfiguracja przez declarative spec (Ignition/machineconfig). - Aktualizacja: nowy obraz OS

(atomic upgrade, reboot).

CIS Benchmark:

Nody muszą spełniać CIS Benchmark Level 2 dla odpowiedniego OS. Weryfikacja: - Automated scan: kube-bench (CIS Kubernetes Benchmark) + CIS-CAT dla OS. - Scan cadence: daily (automated), quarterly (manual review). - Compliance target: 100% PASS (FAIL = P1 defect).

Minimalne pakiety:

Nody robocze zawierają wyłącznie: - Kernel (hardened, eBPF support). - Container runtime (containerd, rootless mode). - kubelet. - SPIRE Agent. - Vault Agent (host-level, dla host secrets). - Network (CNI plugin, IPsec tools). - Monitoring (node_exporter, Tetragon agent).

Brak: SSH daemon (wyłączony domyślnie, enabled only for emergency — Four-Eyes), package manager, compiler, debugger, unnecessary kernel modules.

Kernel hardening:

kernel.kptr_restrict=2 (hide kernel pointers).

kernel.dmesg_restrict=1 (restrict dmesg access).

kernel.yama.ptrace_scope=2 (restrict ptrace to root).

net.ipv4.conf.all.rp_filter=1 (reverse path filtering).

kernel.unprivileged_userns_clone=0 (disable unprivileged user namespaces).

Module loading disabled after boot (kernel.modules_disabled=1).

68.3 Container runtime security — rootless, read-only rootfs, seccomp, AppArmor

Status: [N] Normatywny Odbiorca: DevSecOps, Backend Developer Wpływ na baseline: Krytyczny Powiązane rozdziały: 68.2, 68.4, 62.2

Rootless containers:

Kontenery SYLION uruchamiane jako non-root user (UID ≥ 1000). Dockerfile:

RUN adduser -D -u 1001 sylion USER 1001

Pod Security Standards: restricted profile (Kubernetes PSS).

Read-only rootfs:

securityContext: readOnlyRootFilesystem: true

Writable volumes wyłącznie tam, gdzie konieczne: /tmp (tmpfs, size-limited), /data (dedicated PV). Brak writable layer — malware nie może persystować w filesystem.

Seccomp:

Custom seccomp profile per-service (whitelist dozwolonych syscalls). Domyślny profil SYLION blokuje: - mount, umount — brak mount operations. - ptrace — brak debugging. - clone z CLONE_NEWUSER — brak nowych user namespaces. - kexec_load — brak kernel replacement. - reboot — brak system reboot. - setns — brak namespace switching.

Profile przechowywane w Git, deployowane jako ConfigMap, referenced w Pod spec.

AppArmor:

AppArmor profiles per-service (enforce mode). Profile ograniczają: - File access: whitelist (service binary, config, logs — read-only for most). - Network access: whitelist (bound ports, allowed connections). - Capabilities: deny all except required (e.g., net_bind_service for services on port < 1024).

Pod Security Admission:

Kubernetes Pod Security Admission (PSA) w trybie enforce: restricted na wszystkich namespaces produkcyjnych. Pody naruszające policy → rejected at admission time.

68.4 MicroVM runtime security — Firecracker VMM, minimalny kernel, minimalne virtio

Status: [N] Normatywny Odbiorca: Security Architect, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 67.14, 64.7, 63.4

Firecracker microVM stanowi primary isolation boundary dla workloadów operatorów.

Firecracker hardening:

Jailer: Firecracker uruchamiany przez jailer, który:

Tworzy chroot (izolacja filesystem).

Ustawia cgroups (resource limits: CPU, memory, I/O).

Ustawia seccomp (restrictive profile — dozwolone wyłącznie syscalls wymagane przez VMM).

Ustawia network namespace (izolacja sieci).

Minimal kernel: guest kernel zbudowany z minimalną konfiguracją:

Brak modułów (monolithic kernel).

Brak niepotrzebnych drivers (no USB, no audio, no GPU).

Brak debugfs, tracefs.

Hardened kernel config (KASLR, stack protector, FORTIFY_SOURCE).

- Minimal virtio:
- virtio-block: storage (encrypted).
 - virtio-net: network (per-VM namespace).
 - virtio-vsock: host-guest communication (metrics, health check).
- Brak: virtio-gpu, virtio-input, virtio-serial (nie potrzebne — pixel stream via network).
- SEV-SNP/TDX: memory encryption enabled (jeśli hardware wspiera).
- Boot measurement: measurement guest firmware + kernel → attestation report. Verification przed provisioning sesji.
- Lifecycle:
- MicroVM provisioned per-session (lub per-environment — zależnie od konfiguracji).
 - MicroVM destroyed po zakończeniu sesji (no persistent state — rebuild-first).
 - Snapshot/restore: dozwolone wyłącznie dla pre-provisioned idle VMs (cold start optimization). Snapshot encrypted.

68.5 eBPF / runtime telemetry — Falco, Tetragon

Status: [N] Normatywny Odbiorca: SOC, DevSecOps, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 68.1, 68.7, 67.10

eBPF (extended Berkeley Packet Filter) stanowi fundament runtime telemetry w SYLION. SYLION stosuje Cilium Tetragon (preferowany) lub Falco jako runtime security monitor.

Tetragon — monitoring syscalls:

Tetragon monitoruje syscalls w kernel space (zero overhead na user space) i egzekwuje polityki bezpieczeństwa.

Monitorowane zdarzenia:

Kategoria	Zdarzenia	Alert level
Process	exec, exit, fork	Informational → Alert if unexpected binary
File	open, write, rename, unlink	Alert if sensitive paths (/etc/shadow, /proc, /sys)
Network	connect, accept, sendto, recvfrom	Alert if unexpected destination
Privilege	setuid, setgid, capset	CRITICAL — zawsze alert
Kernel	module_load, kexec, bpf	CRITICAL — zawsze alert

TracingPolicy (Tetragon):

apiVersion: cilium.io/v1alpha1 kind: TracingPolicy metadata: name: sylion-runtime-policy spec: kprobes: - call: "security_file_open" args: - index: 0 type: "file" selectors: - matchArgs: - index: 0 operator: "Prefix" values: ["/etc/shadow", "/proc/kcore"] matchActions: - action: Sigkill # Kill process attempting to read sensitive files

Integration:

Tetragon events → Fluentd/Vector → VictoriaMetrics (metrics) + WORM store (audit) + search index (investigation) + SIEM (external). Real-time alerting via Alertmanager → SOC.

68.6 Egzekwowanie polityk w runtime — OPA sidecar, admission controllers

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 55.7, 68.3, 62.4

Admission Controllers (Kubernetes):

Kubernetes admission controllers egzekwują polityki przy tworzeniu/modyfikacji zasobów:

Pod Security Admission (PSA): enforce restricted profile.

OPA Gatekeeper: custom policies (Rego) weryfikujące:

- Image z approved registry (no Docker Hub direct).
- Image signed (cosign verification).
- No privileged containers.
- Resource limits defined (no unbounded containers).
- Labels required (app, version, owner, tier).
- Network policy exists for namespace.

Kyverno (alternatywa): policy engine z mutation support (auto-inject labels, defaults).

OPA Sidecar (runtime):

OPA sidecar przy każdym mikroserwisie egzekwuje fine-grained authorization (patrz 55.7). Dodatkowo OPA może egzekwować business policies: - Max sessions per-operator per-environment. - Allowed workload types per-tier. - Time-based restrictions (np. no admin operations after hours without SOC approval).

Policy-as-Code:

Wszystkie polityki przechowywane w Git (GitOps). Zmiany polityk: PR → review → test → merge → auto-deploy. Policy drift detection: periodic comparison deployed policies vs Git.

68.7 Anomaly detection — behavioral baselines, ML-assisted

Status: [R] Rekomendowany Odbiorca: SOC, Security Architect, Data Engineer Wpływ na baseline: Średni Powiązane rozdziały: 68.5, 67.12, 64.3

Podejście:

SYLION rekomenduje ML-based anomaly detection jako uzupełnienie rule-based detection. Anomaly detection buduje baseline normalnych zachowań i alertuje na odchylenia.

Źródła danych:

API usage patterns: request volume per-user, per-endpoint, per-hour.

Session patterns: duration, data transfer, time-of-day, frequency.

Network flows: source-destination pairs, volumes, protocols.

Process behavior: syscalls, spawned processes, file access patterns.

Auth patterns: login times, locations, devices, failure rates.

Model:

Baseline: 30-day rolling window per-entity (user, service, operator).

Detection: statistical methods (z-score, IQR) + ML (Isolation Forest, Autoencoder).

Alert: deviations >3σ → alert (low confidence). >5σ → alert (high confidence).

Feedback loop: SOC marks alerts as true/false positive → model retraining.

Ograniczenia:

Cold start: nowy user/service nie ma baseline (30 days to build).

Adaptive attacker: powolna eskalacja (boiling frog) — trudna do wykrycia.

False positives: ML-based detection generuje więcej false positives niż rule-based. Tuning wymagany.

68.8 Wskaźniki naruszenia izolacji — próby ucieczki, syscalls, anomalie sieciowe

Status: [N] Normatywny Odbiorca: SOC, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 67.14, 68.5, 68.9

Indicators of Compromise (IoC) specyficzne dla izolacji SYLION:

Wskaźnik	Opis	Severity	Akcja
ptrace syscall z workloadu	Próba debugowania innego procesu	CRITICAL	Kill + alert + forensics
mount syscall z kontenera	Próba montowania filesystem	CRITICAL	Kill + alert
module_load z VM	Próba załadowania kernel module	CRITICAL	Kill + alert
Connection attempt do metadata service (169.254.169.254)	SSRF / cloud credential theft	HIGH	Block + alert
Connection attempt do innego operatora network	Cross-tenant attempt	CRITICAL	Block + alert + incident
DNS query to unusual domain	Potential C2 communication	MEDIUM	Log + alert (investigate)
Excessive CPU/memory spike	Potential crypto mining or DoS	MEDIUM	Throttle + alert
File write to /tmp exceeding 100MB	Potential staging for exfiltration	MEDIUM	Alert
Unexpected binary execution	Unknown process in workload	HIGH	Alert + investigate
SEV-SNP attestation failure	Potential VM tampering	CRITICAL	Session denied + alert

Automatyczna reakcja:

Wskaźniki CRITICAL → automatyczne działanie (kill, isolate) + alert. Wskaźniki HIGH → alert + SOC review (manual decision). Wskaźniki MEDIUM → log + aggregated review.

68.9 Remediation w runtime — automatyczny restart, izolacja operatora, kaskada alertów

Status: [N] Normatywny Odbiorca: SOC, SRE, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 68.8, 68.1, 62.6

Automatic remediation:

Trigger	Akcja	Eskalacja
Container OOMKill	Auto-restart (max 3x, then halt)	Alert to SRE after 2nd restart
MicroVM crash	Destroy + provision new VM	Alert to SOC
Isolation breach IoC (CRITICAL)	Kill process/VM + network isolate	Alert to SOC (immediate)
Suspected operator compromise	Isolate operator environment (network disconnect)	Alert to SOC + CISO
Policy violation (repeated)	Session terminate + user lockout (30 min)	Alert to operator admin
Health check failure (>3 consecutive)	Pod restart / VM reprovisioning	Alert to SRE

Operator isolation:

W przypadku podejrzenia kompromitacji operatora, SOC może izolować cały operator environment: 1. Network policy update: deny-all ingress/egress do operator namespace. 2. Active sessions terminated. 3. New session creation blocked. 4. Admin notification. 5. Investigation. 6. Restoration after SOC clearance.

Alert cascade:

[IoC detected] → [Tetragon/Falco alert] → [Auto-remediation (if CRITICAL)] → [Alert to SOC (PagerDuty/OpsGenie)] → [SIEM event (external)] → [Audit log (WORM)] → [If unresolved 15min → escalation to SOC Manager] → [If unresolved 1h → escalation to CISO]

68.10 Metryki runtime security

Status: [N] Normatywny Odbiorca: SOC, CISO, SRE Wpływ na baseline: Wysoki Powiązane rozdziały: 56.6, 68.5, 70.11

KPI runtime security:

Metryka	Target	Pomiar
Mean Time to Detect (MTTD)	<5 min (CRITICAL), <30 min (HIGH)	Time from IoC → alert
Mean Time to Contain (MTTC)	<1 min (auto), <15 min (manual)	Time from alert → containment
False Positive Rate	<10% (rule-based), <30% (ML-based)	TP / (TP + FP)
IoC coverage	>95% known attack patterns	Periodic red team validation
Policy compliance	100% workloads with seccomp + AppArmor	Automated scan
CIS benchmark compliance	100% PASS on production nodes	Daily kube-bench scan
Runtime agent coverage	100% nodes with Tetragon agent	Agent health monitoring
Alert response rate	100% CRITICAL within SLA	SOC metrics

Dashboard:

Real-time dashboard: active IoCs, pending alerts, remediation actions, compliance scores, trend charts (weekly/monthly). Dashboard dostępny dla SOC i CISO.

Reporting:

Monthly runtime security report: incidents, IoCs detected, false positive rate, remediation effectiveness, compliance status, improvement recommendations.

Rozdział 69. Supply chain security i CI/CD security

69.1 SBOM — Software Bill of Materials

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 69.2, 69.4, 61.5

SBOM (Software Bill of Materials) jest obowiązkowy dla każdego artefaktu produkcyjnego SYLION: container image, Helm chart, binary, library.

Format:

CycloneDX 1.5+ (JSON) jako primary format. SPDX jako secondary (na żądanie audytora).

Zawartość SBOM:

Wszystkie zależności bezpośrednie i pośrednie (transitive).

Wersje i hash checksums (SHA-256).

Licencje.

Supplier information (upstream maintainer).

Known vulnerabilities (linked to CVE).

Generowanie:

SBOM generowany automatycznie w CI/CD pipeline: - Container images: syft (Anchore) lub trivy sbom. - Go binaries: go mod graph + syft. - Java: cyclonedx-maven-plugin. - Python: cyclonedx-py. - Node.js: cyclonedx-npm.

Publikacja:

SBOM dołączany do artefaktu w OCI registry (cosign attach sbom) i publikowany w SBOM registry (dependency-track lub odpowiednik). Operator STATE może żądać SBOM dla każdego komponentu SYLION.

Monitoring:

Dependency-Track automatycznie skanuje SBOMy pod kątem nowych CVE (continuous monitoring). Alert: nowe CVE CRITICAL w dependency → P1 defect → patch/rebuild w ciągu 72h.

69.2 SCA — Software Composition Analysis

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 69.1, 69.3, 69.9

SCA (Software Composition Analysis) skanuje zależności pod kątem znanych podatności i problemów licencyjnych.

Narzędzia:

Trivy (primary): skanowanie container images, filesystem, IaC.

Snyk lub Gripe (secondary): dodatkowe źródła CVE.

License compliance: FOSSology lub OSV dla licencji.

Pipeline:

SCA uruchamiany: 1. Pre-commit: developer scan (trivy fs .). 2. CI/CD: automated scan na każdym PR. FAIL jeśli: CVE CRITICAL unfixed, CVE HIGH unfixed >7 dni. 3. Registry: continuous monitoring (Dependency-Track). 4. Production: periodic rescan (weekly) production images.

Polityka vulnerability:

Severity	SLA naprawy	Action
CRITICAL	72h	P0 defect, emergency rebuild
HIGH	7 dni	P1 defect, planned rebuild
MEDIUM	30 dni	P2 defect, backlog
LOW	90 dni	P3, best effort

Licencje:

Dozwolone: MIT, Apache 2.0, BSD 2/3-clause, ISC, MPL 2.0 (z review). Zabronione: GPL v2/v3 (copyleft — contamination risk), AGPL, SSPL. Review wymagany: LGPL, CDDL, EPL.

69.3 Dependency pinning — lockfiles, hash verification, brak floating versions

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 69.2, 69.4, 67.8

Reguły:

Lockfiles obowiązkowe: go.sum (Go), package-lock.json (Node.js), Pipfile.lock (Python), pom.xml z explicit versions (Java/Maven), Cargo.lock (Rust).

Hash verification: lockfile musi zawierać hash integrity checksums. npm ci (nie npm install), pip install --require-hashes, go mod verify.

No floating versions: "dependency": "^1.2.3" zabronione w produkcji. Wyłącznie exact pins: "dependency": "1.2.3".

No latest tags: container images pinowane do digest (image@sha256:abc123...), nie tag (image:latest).

Dependency update process: Renovate Bot / Dependabot automatyzuje PR z update'ami zależności. Każdy update: SCA scan + CI tests → merge jeśli green.

Vendoring (opcjonalnie): Go modules vendored (go mod vendor) — eliminacja zależności od zewnętrznego registry w build time.

Monitoring:

Alert jeśli lockfile nie jest aktualny (out-of-sync z manifest). Alert jeśli dependency hash nie pasuje (tamper detection).

69.4 Podpisywanie artefaktów — Sigstore/cosign, keyless signing

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 69.5, 69.6, 61.6

Podpisywanie container images:

Każdy container image produkowany przez CI/CD SYLION jest podpisywany za pomocą cosign (Sigstore):

cosign sign --key vault://transit/sylian-ci-signing \$IMAGE_DIGEST

Klucz podpisu przechowywany w Vault Transit (signing key never exported). Keyless signing (Fulcio + OIDC) jako alternatywa (CI runner identity → short-lived signing cert).

Weryfikacja przy deploy:

Kubernetes admission controller (cosign policy controller / Kyverno) weryfikuje podpis każdego image przed deploying:

apiVersion: kyverno.io/v1 kind: ClusterPolicy metadata: name: verify-images spec: rules: - name: verify-sylian-images match: resources: kinds: [Pod] verifyImages: - image: "registry.sylian.io/*" key: |- -----BEGIN PUBLIC KEY----- ... -----END PUBLIC KEY-----

Image bez valid podpisu → Pod rejected.

Helm charts:

Podpisywane provenance file (helm package --sign). Weryfikacja przy install (helm verify).

Binaries:

CLI tools, SDK packages podpisywane Ed25519. Publiczny klucz publikowany na https://keys.sylian.io/.

69.5 Provenance — SLSA v1.2 Level 3 target, build attestation

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 69.4, 69.6, 69.7

SLSA v1.2 (Supply-chain Levels for Software Artifacts):

SYLION target: SLSA v1.2 Level 3 (build hardened): - Source: Source integrity — git signed commits, protected branches. - Build: Build service is hardened — ephemeral runners, isolated, tamper-resistant. Build process defined as code (Dockerfile, GitHub Actions YAML). - Provenance: Provenance is non-forgable — generated by build service, signed, includes: source repo, commit hash, build inputs, builder identity. - Dependencies: All dependencies pinned and verified.

Build attestation:

Każdy build generuje attestation (SLSA provenance) w formacie in-toto:

```
{ "_type": "https://in-toto.io/Statement/v1", "subject": [{"name": "registry.sylion.io/session-broker", "digest": {"sha256": "abc123..."}}, {"predicateType": "https://slsa.dev/provenance/v1", "predicate": { "buildDefinition": { "buildType": "https://github.com/slsa-framework/slsa-github-generator/...", "externalParameters": {"source": {"uri": "git+https://github.com/sylion/session-broker@refs/heads/main", "digest": {"sha1": "def456"}}, "resolvedDependencies": [...], "runDetails": {"builder": {"id": "https://github.com/slsa-framework/slsa-github-generator/github/workflows/generator_container_slsa3.yml@..."} } } }
```

Attestation podpisana i przechowywana w OCI registry (cosign attach attestation). Weryfikowana przy deploy.

69.6 Reproducible builds — hermetyczne, deterministyczne

Status: [R] Rekomendowany Odbiorca: DevSecOps, Backend Developer Wpływ na baseline: Średni Powiązane rozdziały: 69.5, 69.4, 69.7

Cel:

Reproducible build: ten sam source code + ten sam build environment → identyczny artefakt (bit-for-bit). Umożliwia niezależną weryfikację, że artefakt nie został zmodyfikowany.

Wyzwania:

Timestamps w binary → rozwiązanie: SOURCE_DATE_EPOCH.

Non-deterministic container layers → rozwiązanie: buildkit --metadata-file, deterministic layer ordering.

Go binaries: go build -trimpath -ldflags="-buildid=" → reproducible.

Java: Maven reproducible build plugin, sorted entries in JAR.

Weryfikacja:

CI/CD rebuilds artefakt z tego samego source → porównanie hash. Jeśli hash nie pasuje → alert (non-reproducible build — potential tampering).

Status:

Reproducible builds [R] (rekomendowane) — pełna reprodukowalność jest celem, ale nie wymogiem blokującym (niektóre dependencies nie są reproducible).

Progres monitorowany — target: 80% artefaktów reproducible w ciągu 12 miesięcy.

69.7 Pipeline hardening — least-privilege runners, ephemeral, no persistent credentials

Status: [N] Normatywny Odbiorca: DevSecOps, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 66.8, 69.4, 69.5

Ephemeral runners:

CI/CD runners (GitHub Actions self-hosted, GitLab Runner) są ephemeral: nowy runner per-job, destroyed po zakończeniu. Brak persistent state — secret nie może przetrwać między pipeline'ami.

Implementacja: autoscaling runner pool (Kubernetes-based, clean pod per-job) lub VM-based (Firecracker VM per-job).

Least-privilege:

Runner service account: minimal Kubernetes RBAC (może tworzyć pods w CI namespace, nie w production).

Runner nie ma dostępu do production secrets (dostęp do staging Vault only).

Runner nie ma dostępu do production cluster.

Signing operations: runner wysyła digest do Vault Transit → Vault zwraca podpis. Runner nie posiada signing key.

No persistent credentials:

Vault auth: JWT-based (CI token → Vault policy). Token TTL = pipeline duration.

Registry auth: short-lived token (1h), generated at pipeline start.

Cloud auth: OIDC federation (CI runner → cloud IAM role, no static credentials).

Pipeline isolation:

PR builds: sandbox environment (nie staging, nie production). Brak dostępu do production data.

Merge builds: staging deployment.

Release builds: production deployment (require approval gate — manual or automated security gate).

Audit:

Każdy pipeline execution logowany: kto triggered, jakie secrets accessed, jakie artefakty produced, wynik. Logi pipeline → WORM store.

69.8 Tajemnice w pipeline'ach build

Status: [N] Normatywny Odbiorca: DevSecOps, Backend Developer Wpływ na baseline: Krytyczny Powiązane rozdziały: 66.8, 69.7

Patrz 66.8 dla pełnych reguł. Podsumowanie: - Zero secrets in code/config. - Vault JWT auth for CI. - Ephemeral credentials. - gitleaks pre-commit + CI scan. - Signing via Vault Transit (key never exported).

Dodatkowe: - Build args: secrets przekazywane jako Docker build secrets (--secret), nie ARG (widoczne w image history). - Multi-stage builds: secret dostępny wyłącznie w build stage, nie w final image. - .dockerignore: zawiera .env, *.pem, *.key — nigdy w context.

69.9 Governance zależności — approved registry, vulnerability SLA

Status: [N] Normatywny Odbiorca: DevSecOps, Security Architect, Backend Developer Wpływ na baseline: Krytyczny Powiązane rozdziały: 69.2, 69.3, 61.5

Approved registry:

SYLION wymaga, aby wszystkie zależności pochodziły z approved registries: - Container images: registry.sylion.io (private Harbor registry, mirrored from upstream). - Go modules: GOPROXY pointing to private proxy (Athens). - npm: private Verdaccio/Nexus registry. - PyPI: private devpi/Nexus registry. - Maven: private Nexus registry.

Upstream packages są mirrored po przejściu SCA scan. Bezpośredni pull z publicznego registry (Docker Hub, npmjs.com) w production = policy violation.

Vulnerability SLA:

Patrz 69.2 dla SLA. Dodatkowo: - Dependencies z unfixed CRITICAL CVE >7 dni: automatyczny PR z workaround (downgrade, alternative, in-code mitigation). - Dependencies unmaintained (>12 months no release, no response to CVEs): scheduled replacement (backlog item, P2).

Dependency review:

Nowa zależność (nie istniejąca w approved registry) wymaga review: 1. Developer submits request (name, version, justification). 2. Automated: SCA scan, license check, maintainer activity check. 3. Security review: code review (sampling) for new critical dependencies. 4. Approval → added to approved registry mirror.

69.10 Zarządzanie ryzykiem dostawców

Status: [R] Rekomendowany Odbiorca: CISO, Procurement, Compliance Wpływ na baseline: Średni Powiązane rozdziały: 69.9, 64.1, 59.10

Vendor risk assessment:

Dla krytycznych dostawców (cloud provider, HSM vendor, key OSS dependencies, integration partners):

Security questionnaire: CAIQ (Cloud Security Alliance) lub custom questionnaire.

Certifications: ISO 27001, SOC 2 Type II, CC (Common Criteria) — wymagane dla dostawców T0/T1 infrastructure.

Penetration test results: wymagane od cloud providers i SaaS dependencies.

Business continuity: DR plan, financial stability, single-supplier risk.

Contractual: SLA, data processing agreement, incident notification clause (<24h), audit right.

OSS dependency risk:

Dla krytycznych OSS dependencies (Kubernetes, Envoy, PostgreSQL, Vault, Firecracker): - Maintainer diversity: dependency z single maintainer = risk. Monitoring bus factor. - Funding: preference for well-funded projects (CNCF, Apache Foundation, corporate backing). - Fork readiness: dla ultra-critical dependencies (Firecracker), SYLION maintains fork capability.

69.11 Release promotion gates — security scan → sign → verify → promote

Status: [N] Normatywny Odbiorca: DevSecOps, SRE, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 69.4, 69.5, 70.11

Pipeline promotion:

[Source] → [Build] → [Gate 1: SAST + SCA + SBOM] → [Sign] → [Gate 2: Image scan + Signature verify] → [Staging Deploy] → [Gate 3: DAST + E2E + Contract tests] → [Gate 4: Security approval (automated + manual for HIGH)] → [Production Deploy] → [Gate 5: Post-deploy verification]

Gate details:

Gate	Checks	FAIL action
Gate 1	SAST (no CRITICAL), SCA (no unfixed CRITICAL), SBOM generated	Block build
Gate 2	Container scan (no CRITICAL), cosign signature valid, SLSA attestation present	Block staging deploy
Gate 3	DAST (no CRITICAL), E2E tests pass, contract tests pass	Block production promotion
Gate 4	Security team approval (automated if no HIGH findings, manual if HIGH)	Block production deploy
Gate 5	Health checks pass, smoke tests pass, canary metrics OK (15 min)	Auto-rollback

Fast-track (hotfix):

Emergency security patch: gates 1–3 executed (no skip), gate 4 fast-tracked (CISO approval via Slack/chat), gate 5 normal. Timeline: build-to-production in <2h.

Rozdział 70. Testy bezpieczeństwa i offensive security

70.1 SAST — static analysis, w CI pipeline, zarządzanie false positives

Status: [N] Normatywny Odbiorca: Backend Developer, DevSecOps, QA Wpływ na baseline: Krytyczny Powiązane rozdziały: 69.11, 70.2, 70.11

Narzędzia:

Go: gosec, staticcheck.

Java: SpotBugs + Find Security Bugs, SonarQube.

Python: bandit, semgrep.

TypeScript: semgrep, eslint-plugin-security.

IaC: checkov, tfsec (Terraform), kubesecc (Kubernetes YAML).

Pipeline integration:

SAST uruchamiany na każdym PR. Wyniki: - CRITICAL: block merge. - HIGH: block merge (chyba że acknowledged z justification). - MEDIUM: warning (nie blokuje merge, ale trackowany w backlog). - LOW: informational.

False positive management:

In-code suppression: `// nolint:gosec G404 -- reason lub # nosec z komentarzem justification`.

Centralna baseline: sast-baseline.json per-repo. Known false positives documented. Reviewed quarterly.

Metrics: false positive rate monitorowany. Target: <20% FP. Jeśli >20% → tuning reguł.

70.2 DAST — dynamic testing, staging environment

Status: [N] Normatywny Odbiorca: QA, DevSecOps, Security Architect Wpływ na baseline: Wysoki Powiązane rozdziały: 70.1, 70.3, 69.11

Narzędzia:

OWASP ZAP (primary) lub Burp Suite Enterprise (commercial alternative).

Scope:

DAST uruchamiany na staging environment (nie production) po każdym deployment na staging.

Target:

API endpoints (REST): OWASP ZAP API scan z OpenAPI spec.

Web UI (admin panel, developer portal): ZAP spider + active scan.

Scenariusze:

SQL Injection.

XSS (Reflected, Stored, DOM-based).

CSRF.

Authentication bypass.

Authorization bypass (IDOR).

SSRF.

Header injection.

Open redirect.

Rezultaty:

CRITICAL/HIGH: block production promotion. Fix required.

MEDIUM: tracked in backlog, fix within 30 days.

LOW: informational.

Ograniczenia:

DAST nie pokrywa: business logic flaws, race conditions, cryptographic weaknesses. Te adresowane przez inne metody (code review, threat modeling, fuzzing).

70.3 IAST — runtime instrumentation

Status: [R] Rekomendowany Odbiorca: QA, Backend Developer Wpływ na baseline: Średni Powiązane rozdziały: 70.1, 70.2, 70.4

IAST (Interactive Application Security Testing) łączy zalety SAST i DAST — instrumentacja w runtime pozwala wykrywać podatności z kontekstem execution flow.

Narzędzia:

Contrast Security, Checkmarx IAST, lub OpenTelemetry-based custom instrumentation.

Deployment:

IAST agent deployowany na staging environment. Agent instrumentuje aplikację (bytecode injection w JVM, monkey patching w Python) i analizuje request flow.

Wartość dodana:

Eliminacja false positives: IAST widzi actual execution path (nie guesswork jak SAST).

Coverage: identyfikuje untested code paths.

Real-time: wyniki dostępne natychmiast (nie po batch scan).

Ograniczenia:

Performance overhead (5–15%): nie do production.

Językowa zależność (nie wszystkie języki equally supported).

Status [R]: rekomendowane, nie obowiązkowe (SAST + DAST pokrywają baseline).

70.4 Fuzzing — API, protokoły, formaty plików CDR

Status: [N] Normatywny Odbiorca: Backend Developer, Security Engineer, QA Wpływ na baseline: Wysoki Powiązane rozdziały: 67.7, 67.9, 70.1

API Fuzzing:

Narzędzie: RESTler (Microsoft) lub custom fuzzer oparty na OpenAPI spec.

Target: wszystkie API endpoints na staging.

Strategia: generowanie losowych requestów zgodnych z schematem (valid structure, invalid values).

Cel: wykrywanie crashy, 5xx errors, timeout, unexpected behavior.

Cadence: weekly (automated).

Protocol Fuzzing:

Target: IPsec IKEv2 implementation, TLS stack, gRPC parser.

Narzędzie: AFL++ lub LibFuzzer.

Cel: wykrywanie memory corruption, parsing errors, DoS.

Cadence: per-release (major/minor version).

File Format Fuzzing (CDR):

Target: CDR engine (parsery Office, PDF, images).

Narzędzie: AFL++ z corpus of malicious documents (VirusTotal samples, publicly available malware corpora).

Cel: wykrywanie crashy, RCE, parsing bypasses w CDR.

Cadence: continuous (background job).

Szczególna uwaga: CDR jest critical control — bypass CDR = malware delivery. Fuzzing CDR jest obowiązkowe (nie rekomendowane).

70.5 Infrastructure scanning — Terraform plan analysis, config drift

Status: [N] Normatywny Odbiorca: DevSecOps, SRE Wpływ na baseline: Wysoki Powiązane rozdziały: 60.11, 68.6, 70.6

Terraform scanning:

terraform plan output analizowany przez checkov / tfsec / OPA conftest.

Polityki: no public S3 buckets, no open security groups, encryption required, logging enabled.

Pipeline: scan on PR → FAIL if policy violation → block merge.

Config drift detection:

GitOps: desired state in Git. Actual state in cluster.

Drift detection: ArgoCD / Flux reconciliation. Drift → alert + auto-reconcile (lub block depending on policy).

Infrastructure drift: terraform plan (periodic, no apply) — detect differences between Terraform state and actual infrastructure.

Cadence: daily (drift scan), real-time (GitOps reconciliation).

70.6 Configuration validation — CIS benchmarks, custom policies

Status: [N] Normatywny Odbiorca: DevSecOps, SRE, Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 68.2, 62.10, 70.5

CIS Benchmarks:

Kubernetes: kube-bench (CIS Kubernetes Benchmark). Daily scan. 100% PASS required.

OS: CIS-CAT (CIS Benchmark for OS). Daily scan.

PostgreSQL: CIS PostgreSQL Benchmark. Weekly scan.

Docker: Docker Bench for Security. Per-image scan in CI.

Custom policies:

SYLION-specific policies (beyond CIS): - No containers with latest tag. - All pods have resource limits. - All namespaces have NetworkPolicy. - All PVs encrypted. - Vault auto-unseal configured. - Backup encryption verified.

Custom policies implementowane jako OPA Gatekeeper ConstraintTemplates lub Kyverno policies.

Compliance dashboard:

Real-time dashboard: CIS compliance score per-node, per-namespace. Trend charts. Drill-down do specific failures. Dashboard dostępny dla CISO i Compliance.

70.7 Red teaming — scope, rules of engagement, raportowanie

Status: [N] Normatywny Odbiorca: CISO, Security Architect, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 70.8, 70.9, 64.1

Częstotliwość:

Annual red team exercise (minimum). Dla tier STATE: semi-annual.

Scope:

Pełna infrastruktura SYLION: external (internet-facing), internal (post-breach simulation), social engineering (phishing, pretexting), physical (datacenter access — jeśli applicable).

Rules of Engagement:

Scope agreement: written document, approved by CISO.

No-go areas: production data destruction, actual customer data access (synthetic only), DoS on production (staging OK).

Communication: secure channel between red team lead and CISO.

Emergency stop: CISO can halt exercise at any time.

Deconfliction: red team activities logged (separate from production audit) to distinguish from real attacks.

Raportowanie:

Executive summary: overall security posture, critical findings.

Technical report: per-finding (vulnerability, PoC, impact, remediation).

MITRE ATT&CK mapping: TTPs used, detection rate, gaps.

Remediation plan: per-finding, owner, deadline, priority.

Tracking:

Findings tracked in dedicated tracker (Jira project). SLA: CRITICAL fix <30 days, HIGH <60 days, MEDIUM <90 days. Retest after fix (verification by red team).

70.8 Purple teaming — atak + obrona jednocześnie, tuning detekcji

Status: [R] Rekomendowany Odbiorca: SOC, Security Architect Wpływ na baseline: Wysoki Powiązane rozdziały: 70.7, 70.9, 68.7

Koncepcja:

Purple team = red team (attack) + blue team (defense) współpracujący w real-time. Red team wykonuje technikę ataku, blue team próbuje wykryć i zareagować. Natychmiastowy feedback loop.

Cel:

Testowanie skuteczności detekcji (Tetragon, Falco, SIEM rules, anomaly detection).

Tuning alertów (zmniejszenie FP, zwiększenie TP).

Budowanie wspólnej wiedzy (red + blue understanding).

Cadence:

Quarterly purple team sessions (4h–8h each). Focus per-session: jedna domena (np. lateral movement, credential theft, exfiltration).

Rezultat:

Per-session: lista przetestowanych TTPs, detection rate (%), nowe/zmodyfikowane detection rules, action items.

70.9 Adversary simulation — scenariusze APT, testowanie kill chain

Status: [R] Rekomendowany Odbiorca: SOC, CISO, Security Architect Wpływ na baseline: Wysoki Powiązane rozdziały: 64.1, 70.7, 70.8

Scenariusze:

Symulacja pełnych kill chains dla zdefiniowanych klas przeciwników (patrz 64.1):

Opportunistic attacker: automated scan → exploit internet-facing service → lateral movement → data exfiltration.

Organized crime: targeted phishing → credential theft → session hijack → financial fraud.

Corporate espionage: insider recruitment → data exfiltration → cover tracks.

Nation-state (SIGINT): supply chain compromise → persistent access → long-term surveillance.

Malicious insider: privilege abuse → data exfiltration → log tampering attempt.

Narzędzia:

MITRE ATT&CK Navigator (planning), Atomic Red Team (individual TTPs), Caldera (automated adversary emulation).

Metryki:

Dwell time: jak długo atakujący może być w sieci niezauważony.

Detection rate: % technik wykrytych.

Response time: czas od detection do containment.

70.10 Bug bounty / responsible disclosure

Status: [R] Rekomendowany Odbiorca: CISO, Security Team, Legal Wpływ na baseline: Średni Powiązane rozdziały: 70.7, 67.1, 64.1

Program:

Private bug bounty program (HackerOne lub Bugcrowd) z zaproszeniem (nie publiczny, przynajmniej początkowo).

Scope:

In-scope: API Gateway, authentication endpoints, web portal, SDK libraries.

Out-of-scope: DDoS, social engineering on employees, physical access.

Nagrody:

Severity	Nagroda
CRITICAL (RCE, auth bypass, data breach)	5 000–20 000 EUR
HIGH (privilege escalation, IDOR, stored XSS)	2 000–5 000 EUR
MEDIUM (reflected XSS, CSRF, info disclosure)	500–2 000 EUR
LOW (header misconfiguration, verbose errors)	100–500 EUR

Responsible disclosure policy:

Publicznie dostępna na <https://syllion.io/.well-known/security.txt> (RFC 9116):

Contact: <mailto:security@syllion.io> Encryption: <https://keys.syllion.io/security-pgp.asc> Preferred-Languages: en, pl, de Canonical: <https://syllion.io/.well-known/security.txt> Policy: <https://syllion.io/security/disclosure-policy> Hiring: <https://syllion.io/careers/security>

SLA response:

Acknowledgment: <24h.

Triage: <72h.

Fix: per severity SLA (69.2).

Disclosure: coordinated, 90-day window.

70.11 Governance testów bezpieczeństwa — ownership, kadencja, metryki, progi

Status: [N] Normatywny Odbiorca: CISO, Security Architect, QA Wpływ na baseline: Krytyczny Powiązane rozdziały: 70.1–70.10, 69.11

Ownership:

Test type	Owner	Executor	Cadence
SAST	Security Team (rules), Dev Team (execution)	CI/CD (automated)	Every PR
DAST	Security Team	CI/CD (automated)	Every staging deploy
IAST	Security Team	QA	Weekly (staging)
Fuzzing (API)	Security Team	CI/CD (automated)	Weekly
Fuzzing (CDR)	Security Team	Background job	Continuous
Infra scan	DevSecOps	CI/CD + scheduled	Daily
CIS benchmark	DevSecOps	Automated	Daily
Red team	CISO	External vendor or internal red team	Annual
Purple team	SOC + Security	Internal	Quarterly
Adversary sim	SOC	Internal or external	Semi-annual
Bug bounty	Security Team	External researchers	Continuous

Metryki:

Metryka	Target
SAST finding density (CRITICAL+HIGH per KLOC)	<1
DAST finding density (CRITICAL+HIGH per endpoint)	<0.1
Vulnerability SLA compliance	>95%
Red team finding fix rate (within SLA)	100%
Bug bounty response SLA compliance	>95%
False positive rate (SAST)	<20%
Fuzzing crash count (CDR)	0 unresolved CRITICAL
CIS benchmark compliance	100% PASS

Progi (thresholds):

Merge block: any CRITICAL (SAST, DAST, SCA).

Deploy block: any CRITICAL unfixed, HIGH unfixed >7 days.

Release block: red team CRITICAL finding unfixed.

Escalation: vulnerability SLA compliance <90% → CISO review. ## ## Rozdział 71. Katalog ataków i odpowiadające im środki ochronne

71.1 Zajęcie terminala

Status: [N] Normatywny Odbiorca: CISO, Security Architect, SOC, Legal Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.4, 63.1, 71.2

Opis ataku: Atakujący uzyskuje fizyczny dostęp do terminala użytkownika (kradzież, konfiskata, znalezienie bez nadzoru).

Profil atakującego: Klasa 1 (oportunistyczny — kradzież), Klasa 4 (państwowy — konfiskata), Klasa 7 (prawno-procesowy — zajęcie na podstawie nakazu).

Kontrolki SYLION: 1. Full-disk encryption (LUKS/BitLocker z pre-boot auth) — dane na dysku niedostępne bez hasła/PIN. 2. Thin client — zero local data. Brak treści komunikacji, dokumentów, kluczy sesji na urządzeniu. 3. Auto-wipe po N failed PIN attempts (konfigurowalny, default 10). 4. Remote wipe via MDM. 5. FIDO2 security key — klucz sesji jest na osobnym urządzeniu (nie na laptopie). Kradzież laptopa bez klucza FIDO2 = brak dostępu. 6. Session auto-terminate: brak aktywności >timeout → sesja zakończona po stronie serwera.

Blast radius: Zero danych operatora. Atakujący posiada zaszyfrowany dysk i pustego thin clienta.

Detekcja: Session terminated (server-side). MDM device offline alert. Operator powiadamia SOC → remote wipe.

Remediation: Remote wipe. Credential revocation (FIDO2 key de-registration jeśli skradziony). Nowy terminal provisioned.

71.2 Przymus fizyczny (physical coercion)

Status: [N] Normatywny Odbiorca: CISO, Legal, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 63.1, 64.11, 71.1

Opis ataku: Użytkownik zmuszony do zalogowania się pod przymusem (szantaż, groźba, przesłuchanie, kryptoanaliza gumową pałką).

Profil atakującego: Klasa 2–4 (przestępcy, służby), Klasa 7 (prawny — nakaz ujawnienia hasła).

Kontrolki SYLION: 1. Duress PIN [O] (STATE): specjalny PIN/hasło, które pozornie loguje użytkownika, ale: sesja z ograniczonymi/fałszywymi danymi, cichy alert do SOC, automatyczne nagrywanie sesji. 2. Operator nie posiada danych: filozofia Zero Knowledge — operator admin nie ma kluczy E2EE, nie ma dostępu do treści komunikacji. Nie może „wydać” czegoś, czego nie posiada. 3. Session broker kontrolowany server-side: nawet jeśli użytkownik zaloguje się pod przymusem, sesja jest brokowana — serwer może ograniczyć dostęp (policy-based). 4. Krótkie retencje: dane automatycznie usuwane — informacje sprzed N dni mogą już nie istnieć.

Blast radius: Ograniczony do danych aktualnie dostępnych w sesji użytkownika. Brak dostępu do danych innych użytkowników, historycznych komunikacji (E2EE), management plane.

Detekcja: Duress PIN → cichy alert SOC. Anomaly detection (login z nieznanej lokalizacji/urządzenia w kontekście stresu).

Remediation: SOC investigation. Session revocation. Credential rotation. Legal counsel.

71.3 Utrata routera

Status: [N] Normatywny Odbiorca: Security Architect, Network Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 64.5, 65.1, 71.4

Opis ataku: Router sieciowy (ISP, corporate) między terminalem a SYLION zostaje przejęty lub podmieniony.

Profil atakującego: Klasa 2–4.

Kontrolki SYLION: 1. IPsec IKEv2 (end-to-end encryption Zone 0–1). Router widzi wyłącznie zaszyfrowane pakiety ESP. 2. Certificate-based auth — router nie może wykonać MITM (nie posiada certyfikatu Zone 1 gateway). 3. PFS — przechwycony ruch nie może być odszyfrowany retroaktywnie.

Blast radius: Zero. Atakujący widzi zaszyfrowany ruch. Nie może odszyfrować ani zmodyfikować.

Detekcja: Zmiana latencji/routing path (traceroute monitoring). Certificate mismatch (jeśli MITM attempt).

Remediation: Zmiana trasy sieciowej. Powiadomienie ISP. Jeśli MITM attempt wykryty — rotacja session keys (PFS handles this automatically).

71.4 Tower dumps i IMSI catchers

Status: [N] Normatywny Odbiorca: CISO, Security Architect Wpływ na baseline: Wysoki Powiązane rozdziały: 64.9, 63.1

Opis ataku: Służby lub atakujący z dostępem do infrastruktury telekomunikacyjnej zbierają IMSI urządzeń podłączonych do stacji bazowej (tower dump) lub używają IMSI catchera (fałszywa stacja bazowa).

Profil atakującego: Klasa 4 (SIGINT), Klasa 7 (prawny — nakaz dla operatora telekom).

Kontrolki SYLION: 1. IPsec tunnel — niezależny od szyfrowania GSM/LTE. IMSI catcher widzi zaszyfrowany tunel. 2. IMSI rotation (legalna — Cape MVNO): zmiana IMSI utrudnia korelację. Uwaga: IMEI modification jest nielegalna w EU/UK/India/Australia i nie jest wspierana. 3. Brak korelacji IMSI-tożsamość SYLION: SYLION nie przechowuje IMSI użytkowników. 4. Traffic padding [O]: utrudnia traffic analysis.

Blast radius: Atakujący uzyskuje: IMSI urządzenia (jeśli bez rotation), lokalizację cell tower, timing komunikacji. Nie uzyskuje: treści komunikacji, tożsamości SYLION, danych sesji.

Detekcja: Dedykowane narzędzia IMSI catcher detection (AIMSICD, SnoopSnitch) — opcjonalne, po stronie użytkownika.

Remediation: IMSI rotation. VPN jako dodatkowa warstwa. Zmiana lokalizacji (jeśli targeted).

71.5 Złośliwy załącznik — łańcuch CDR

Status: [N] Normatywny Odbiorca: SOC, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 67.9, 58.5

Opis ataku: Atakujący przesyła malicious document (macro-enabled Office, PDF exploit, polyglot file) przez kanał komunikacyjny SYLION.

Profil atakującego: Klasa 1–3.

Kontrolki SYLION: 1. CDR pipeline: plik przechodzi Content Disarm & Reconstruct. Macra usunięte, JavaScript usunięty, embedded objects usunięte, metadata stripped. 2. Format whitelist: tylko dozwolone formaty (docx, xlsx, pdf, png, jpg). Nieznane → zablokowane. 3. File size limit: max file size per-policy (default 25MB). 4. Sandbox analysis [R]: opcjonalna detonacja w sandbox (mikro-VM) przed dostarczeniem. 5. No direct execution: plik po CDR otwarty w server-side application (pixel stream). Nawet jeśli CDR nie usunie exploit — exploit wykonuje się w izolowanym microVM, nie na terminalu użytkownika.

Blast radius: Jeśli CDR działa prawidłowo → zero. Jeśli CDR bypass → exploit w microVM operatora (izolowany, patrz 67.14). Nie wpływa na inne operatorów ani platformę.

Detekcja: CDR logs (ile plików zmodyfikowanych, ile quarantined), sandbox alerts, Tetragon runtime monitoring w microVM.

Remediation: Quarantine oryginalnego pliku. Analiza SOC. Update CDR rules jeśli bypass wykryty.

71.6 Kompromitacja session brokera

Status: [N] Normatywny Odbiorca: Security Architect, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.6, 67.13

Opis ataku: RCE na session brokerze (np. Guacamole CVE-2024-35164) — atakujący uzyskuje kontrolę nad komponentem Zone 2.

Profil atakującego: Klasa 1–4.

Kontrolki SYLION: 1. Patching (emergency, <24h od CVE disclosure). 2. Sandboxing: Guacamole w microVM (Firecracker + SEV-SNP). 3. Horizontal scaling: kompromitacja jednego noda ≠ wszystkie sesje. 4. Credential limitation: broker ma minimalne uprawnienia. 5. Runtime monitoring (Tetragon). 6. Network isolation: broker nie ma dostępu do Zone 5.

Blast radius: Sesje aktywne na skompromitowanym nodzie: pixel stream potencjalnie przechwycony. Brak dostępu do: management plane, Vault, baz danych (poza session metadata), innych operatorów (na innych nodach).

Detekcja: Runtime IoC (unexpected processes, network connections, file modifications).

Remediation: Isolate compromised node. Terminate affected sessions. Migrate sessions to clean nodes. Forensics. Rebuild.

71.7 Kompromitacja workloadu

Status: [N] Normatywny Odbiorca: Security Architect, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 67.14, 68.4, 64.7

Opis ataku: Atakujący uzyskuje kontrolę nad workloadem operatora (microVM) — przez exploit w aplikacji, malicious document (post-CDR bypass), lub insider.

Profil atakującego: Klasa 1–5.

Kontrolki SYLION: 1. MicroVM isolation (Firecracker) — VM escape wymagany do lateral movement. 2. SEV-SNP/TDX — memory encryption (host nie ma dostępu do plaintext pamięci VM). 3. Network microsegmentation — workload nie ma dostępu do innych operatorów. 4. Short-lived credentials — tokens w VM wygasają w minutach. 5. Egress deny-default — exfiltration zablokowane. 6. Runtime monitoring — Tetragon wykrywa anomalne zachowania.

Blast radius: Dane operatora w danym environment (nie innych operatorów). Ograniczony do tego, co jest dostępne w ramach sesji/workloadu.

Detekcja: Runtime IoC, network anomalies, egress attempts.

Remediation: Kill VM. Destroy and rebuild environment. Credential rotation for operator. Forensics on VM snapshot.

71.8 Hostile hypervisor (SEV-SNP + TDX analysis)

Status: [N] Normatywny Odbiorca: CISO, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.7, 64.8

Opis ataku: Cloud provider lub atakujący z dostępem do hypervisora próbuje odczytać pamięć VM, zmodyfikować firmware, przechwycić dane.

Profil atakującego: Klasa 6 (hostile hypervisor), Klasa 4 (nation-state z prawnym dostępem do providera).

Kontrolki SYLION: 1. SEV-SNP: memory encryption (AES-128 per-VM key, managed by AMD PSP). 2. TDX: memory encryption (AES-128 per-TD key, managed by Intel TDX module). 3. Attestation: weryfikacja integralności VM przed uruchomieniem. 4. Encryption at-rest: dane na dysku zaszyfrowane kluczem klienta (nie providera). 5. Network encryption: IPsec/mTLS — provider widzi ciphertext.

Analiza CVE: - AMD SEV-SNP: 49 CVE w historii. CVE-2024-56161 (firmware injection), Battering RAM (memory read). Trend: ciągle odkrywanie nowych podatności. - Intel TDX: 9 CVE w historii. Nowsza technologia, mniej przetestowana. - Wniosek: TEE to wartościowa warstwa, ale nie absolutna gwarancja. Traktować jako defense-in-depth.

Blast radius: Przy skutecznym ataku na TEE: dostęp do pamięci VM (potencjalnie klucze sesji, dane w przetwarzaniu). Ograniczony do jednej VM (per-operator isolation). Brak dostępu do innych operatorów (separate VMs, separate keys).

Detekcja: Attestation failure (modified firmware/measurement). Anomalous hypervisor behavior (trudne do wykrycia z wnętrza VM).

Remediation: Migration to different host/provider. Autonomous perimeter [A] (eliminacja cloud provider). Key rotation.

71.9 Memory scraping (SEV-SNP mitigations + residual risk)

Status: [N] Normatywny Odbiorca: Security Architect, CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.7, 71.8

Opis ataku: Atakujący (z dostępem do hosta) próbuje odczytać pamięć VM (cold boot attack, memory dump, DMA attack, hypervisor-level read).

Kontrolki SYLION: 1. SEV-SNP/TDX: pamięć zaszyfrowana sprzętowo. Hypervisor i host OS nie mogą odczytać plaintext. 2. IOMMU (Intel VT-d / AMD-Vi): ochrona przed DMA attacks (peripheral devices nie mogą czytać pamięci VM). 3. Secure wipe: credentials w pamięci zerowane po użyciu (explicit_bzero). 4. No swap: swap disabled lub encrypted. 5. No core dumps: core dumps disabled dla procesów z secrets.

Residual risk: - SEV-SNP bypass (CVE history — patrz 71.8). Atakujący z 0-day na SEV-SNP może odczytać pamięć. - Cold boot attack na host (przed SEV-SNP encryption takes effect — narrow window at boot). - Hardware-level attack (physical tampering z memory bus — wymagane zaawansowane laboratorium).

Blast radius: Dane aktualnie w pamięci VM (klucze sesji, przetwarzane dokumenty). Short-lived credentials minimalizują wartość — klucz sesji ważny 15 min.

71.10 Zajęcie serwera

Status: [N] Normatywny Odbiorca: CISO, Legal, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.11, 66.10

Opis ataku: Organy ścigania fizycznie zajmują serwery SYLION (datacenter raid, confiscation).

Profil atakującego: Klasa 7 (prawno-procesowy).

Kontrolki SYLION: 1. Encryption at-rest (LUKS): dyski zaszyfrowane. Bez klucza → ciphertext. 2. Vault sealed at power-off: automatyczne zapieczętowanie. Unseal wymaga KMS/HSM access. 3. SEV-SNP: pamięć encrypted at-rest (po power-off → garbage). 4. Short-lived credentials: po power-off → wszystkie tokeny/certy expired. 5. Data minimization: krótkie retencje → dane mogą już nie istnieć. 6. Auto-lockdown: anomaly detection (multiple nodes offline) → remaining nodes seal Vault, terminate sessions, alert CISO. 7. BYO-KMS (STATE): operator kontroluje klucze — SYLION nie może odszyfrować nawet pod nakazem.

Blast radius: Atakujący posiada: zaszyfrowane dyski (LUKS), sealed Vault, expired credentials. Bez klucza szyfrowania: zero użytecznych danych.

Detekcja: Physical security alerts. Multiple-node offline anomaly.

Remediation: Legal counsel. DR activation (failover to secondary site). Credential rotation. CISO notification.

71.11 Kompromitacja management plane

Status: [N] Normatywny Odbiorca: CISO, Security Architect Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.13, 63.6

Opis ataku: Atakujący uzyskuje dostęp do Zone 5 (management plane) — najpoważniejszy scenariusz.

Profil atakującego: Klasa 4 (APT), Klasa 5 (insider), Klasa 6 (hostile provider).

Kontrolki SYLION: 1. Zone 5 jest najbardziej chroniona (patrz 63.6). 2. FIDO2 + step-up + Four-Eyes dla każdej operacji. 3. Dedicated admin network (bastion host). 4. Minimal exposure: Zone 5 nie jest dostępna z Zone 0–3. 5. Complete audit trail (WORM, hash chains). 6. Behavioral monitoring: anomaly detection na admin activity. 7. Segregation of duties: żadna osoba nie ma pełnych uprawnień.

Blast radius: Potencjalnie katastrofalny: pełna kontrola nad platformą. Mitygacja: nawet z dostępem do Zone 5, atakujący potrzebuje: FIDO2 credential (hardware), drugiej osoby (Four-Eyes), znajomości procedur. Każde działanie logowane w tamper-evident audit log.

Detekcja: Unusual admin activity, Four-Eyes bypass attempt, unexpected API calls from Zone 5.

Remediation: Immediate lockdown. Vault re-seal. Full audit review. Credential rotation (all tiers). Forensics. Potentially: full platform rebuild.

71.12 Wyciek optyczny (optical leak)

Status: [O] Opcjonalny (watermarking), [N] Normatywny (polityki) Odbiorca: CISO, SOC, HR Wpływ na baseline: Wysoki Powiązane rozdziały: 64.10

Opis ataku: Użytkownik fotografuje ekran, nagrywa screencast, lub manualnie kopiuje dane (paper-based exfiltration).

Profil atakującego: Klasa 5 (insider), Klasa 3 (corporate espionage).

Kontrolki SYLION: 1. Micro-watermarking [O] (DCT steganographic): identyfikacja źródła wycieku. 2. Clipboard/print/download controls (default: disabled). 3. Session recording (opt-in). 4. Physical security policies (no phones in secure areas — organizational control). 5. DLP rules [R] (detect sensitive content in viewport).

Blast radius: Dane widoczne na ekranie w momencie wycieku. Ograniczone do tego, co użytkownik widzi (least privilege ogranicza scope).

Detekcja: Watermark forensics (post-facto). Screen capture detection (limited effectiveness).

Remediation: Forensic analysis (watermark → identification of source). Disciplinary/legal action. Policy review.

71.13 Nadużycie uprawnień (privilege abuse)

Status: [N] Normatywny Odbiorca: CISO, SOC, HR Wpływ na baseline: Krytyczny Powiązane rozdziały: 64.3, 62.2, 62.3

Opis ataku: Uprzywilejowany użytkownik (admin, SOC, developer) nadużywa swoich uprawnień do nieautoryzowanego dostępu lub modyfikacji.

Profil atakującego: Klasa 5 (malicious insider).

Kontrolki SYLION: 1. Least privilege: minimalne uprawnienia per-role. 2. Segregation of duties: żadna rola nie ma pełnej kontroli. 3. Four-Eyes: operacje krytyczne wymagają drugiej osoby. 4. WORM audit logs: wszystkie działania logowane, nie mogą być usunięte. 5. Behavioral analytics: anomaly detection na admin activity. 6. Temporary elevation: eskalacja uprawnień wymaga approval, jest czasowa (4h), logowana. 7. Access reviews: quarterly review uprawnień (who has access to what, is it still justified).

Blast radius: Ograniczony do scope uprawnień roli. Admin nie ma dostępu do treści komunikacji (E2EE). SOC nie może modyfikować polityk. Developer nie ma dostępu do produkcji.

Detekcja: UEBA, audit log analysis, peer review (unusual approvals w Four-Eyes).

Remediation: Revoke access. Investigation. Credential rotation. Disciplinary action.

71.14 Analiza ruchu i korelacja metadanych

Status: [N] Normatywny Odbiorca: Security Architect, CISO Wpływ na baseline: Wysoki Powiązane rozdziały: 64.9, 65.1

Opis ataku: Atakujący (z dostępem do sieci) analizuje zaszyfrowany ruch: timing, volume, patterns, source/dest IP, aby wyciągnąć wnioski o aktywności użytkowników.

Profil atakującego: Klasa 4 (SIGINT), Klasa 6 (network provider).

Kontrolki SYLION: 1. IPsec/mTLS: treść komunikacji zaszyfrowana. Atakujący widzi ciphertext. 2. Traffic padding [O]: generowanie dummy traffic aby zaburzyć timing analysis. 3. Centralized gateway: wszystkie połączenia przez Zone 1 gateway (nie bezpośrednie połączenia do poszczególnych serwisów). Atakujący widzi: user → gateway. Nie widzi: gateway → specific service. 4. Short sessions: session timeout minimalizuje time-correlation. 5. E2EE: nawet SYLION nie ma metadanych treści.

Blast radius: Atakujący uzyskuje: timing aktywności (kiedy użytkownik jest online), volume (ile danych przesyłanych), destination IP (gateway — nie specific service). Nie uzyskuje: treści, tożsamości SYLION, konkretnych operacji.

Detekcja: Trudna (atakujący jest pasywny). Monitoring: anomalie w routingu (BGP hijack), unusual latency patterns.

Remediation: Traffic padding [O]. Multi-path routing. VPN as additional layer.

71.15 Kompromitacja supply chain

Status: [N] Normatywny Odbiorca: CISO, DevSecOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 67.8, 69.1–69.11

Opis ataku: Kompromitacja zależności, build narzędzi, CI/CD pipeline, container registry. Backdoor w upstream dependency.

Profil atakującego: Klasa 2–4 (sophisticated supply chain attacks: xz-utils, SolarWinds).

Kontrolki SYLION: 1. SBOM: pełna widoczność zależności. 2. SCA: continuous vulnerability scanning. 3. Dependency pinning + hash verification. 4. Artifact signing (cosign/Sigstore). 5. SLSA v1.2 Level 3 provenance. 6. Approved registry (no direct pulls from public). 7. Ephemeral CI runners. 8. Reproducible builds (target). 9. Vendor risk assessment.

Blast radius: Potencjalnie szeroki — skompromitowana zależność może dotknąć wiele serwisów. Mitygacja: blast radius reduction przez microservices (nie monolith), szybka detekcja (SBOM monitoring), rapid rebuild.

Detekcja: SCA alerts (new CVE), SBOM diff (unexpected dependency change), provenance verification failure, build reproducibility mismatch.

Remediation: Identify affected artifacts. Rebuild from known-good sources. Emergency deploy. Notify operators. Post-incident: vendor review, dependency replacement if needed.

71.16 Tabela podsumowująca: atak → primary control → blast radius → detekcja → remediation

Status: [N] Normatywny Odbiorca: CISO, Security Architect, Board, Auditor Wpływ na baseline: Krytyczny Powiązane rozdziały: 71.1–71.15, 64.1, 64.12

#	Scenariusz ataku	Primary Control	Blast Radius	Detekcja	Remediation
71.1	Zajęcie terminala	FDE + thin client + FIDO2	Zero danych operatora	MDM offline alert	Remote wipe, new terminal
71.2	Przymus fizyczny	Duress PIN [O] + zero knowledge	Dane widoczne w sesji	Duress alert do SOC	Credential revoke, legal
71.3	Utrata routera	IPsec IKEv2 + cert auth + PFS	Zero (ruch zaszyfrowany)	Latency/route change	Zmiana trasy
71.4	Tower dump / IMSI catcher	IPsec + IMSI rotation	IMSI + location + timing	IMSI catcher detection tools	IMSI rotation, VPN
71.5	Złośliwy załącznik	CDR pipeline	Zero (CDR effective) lub microVM (CDR bypass)	CDR logs, sandbox alerts	Quarantine, CDR update
71.6	Kompromitacja brokera	MicroVM sandbox + horizontal scaling	Sesje na jednym nodzie	Runtime IoC (Tetragon)	Isolate, rebuild, migrate
71.7	Kompromitacja workloadu	Firecracker + SEV-SNP + microseg	Dane jednego operatora/env	Runtime monitoring	Kill VM, rebuild env
71.8	Hostile hypervisor	SEV-SNP/TDX + encryption + attestation	Potencjalnie pamięć jednej VM	Attestation failure	Migration, autonomous perimeter
71.9	Memory scraping	SEV-SNP + IOMMU + secure wipe	Dane w pamięci (short-lived)	Difficult (hardware-level)	Key rotation, migration
71.10	Zajęcie serwera	LUKS + Vault seal + BYO-KMS	Zero (dane zaszyfrowane)	Physical alerts, multi-node offline	DR activation, legal
71.11	Management plane compromise	FIDO2 + Four-Eyes + Zone 5 isolation	Potencjalnie cała platforma	Admin anomaly detection	Lockdown, full audit, rebuild
71.12	Wyciek optyczny	Watermarking [O] + policies	Dane na ekranie	Watermark forensics	Investigation, disciplinary
71.13	Nadużycie uprawnień	Least privilege + Four-Eyes + WORM	Scope roli (nie cały system)	UEBA, audit logs	Access revoke, investigation
71.14	Traffic analysis / metadata	IPsec + traffic padding [O]	Timing + volume + dest IP	Passive (trudna)	Traffic padding, multi-path
71.15	Supply chain compromise	SBOM + SCA + signing + SLSA L3	Wiele serwisów (potencjalnie)	SCA alerts, SBOM diff	Rebuild, emergency deploy

Interpretacja tabeli:

Kolumna „Primary Control” wskazuje najważniejszą (nie jedyną) kontrolkę. W praktyce defense-in-depth łączy wiele kontrolkek (patrz odpowiednie podrozdziały 71.1–71.15).

Kolumna „Blast Radius” opisuje worst-case z uwzględnieniem kontrolkek SYLION (nie worst-case bez kontrolkek).

Scenariusze z blast radius „Potencjalnie cała platforma” (71.11) wymagają najsilniejszych kontrolkek i najmniejszego ryzyka rezydualnego.

Oznaczenia [O] przy kontrolkach wskazują, że kontrolka jest opcjonalna — operator STATE powinien ją włączyć dla najwyższego poziomu ochrony.

Niniejsza tabela stanowi narzędzie referencyjne dla CISO, audytorów i architektów bezpieczeństwa. Przegląd co 6 miesięcy — aktualizacja na podstawie nowych CVE, incydentów i zmian w krajobrazie zagrożeń. # SYLION 3.0 — Księga Systemu

Podsystem streamingu i komunikacji real-time — model decyzyjny

Status: [N] Normatywny (Model A) | [E] Eksperymentalny (Model B) | Odbiorca: Architekt | Dev | Infra | Wpływ na baseline: Krytyczny | Powiązane rozdziały: 124.1, 32–51, 62–71

Podsystem streamingu obsługuje dwa fundamentalnie różne kanały: (A) remote workspace — transport skompresowanego obrazu ekranu roboczego operatora, oraz (B) media E2EE — szyfrowane ramki audio i wideo przed opuszczeniem środowiska aplikacji. Oba kanały mają odmienne właściwości bezpieczeństwa, różny poziom dojrzałości i różne wymagania certyfikacyjne.

Model A — Remote Desktop / App Publishing [N]: Produkcyjny baseline dla SYLION 3.0. Sesja zdalna transportuje skompresowany obraz ekranu szyfrowany w tunelu IPsec IKEv2 (AES-256-GCM). Broker sesji (Apache Guacamole lub Keeper Connection Manager) widzi strumień w plaintext w obrębie zaufanego środowiska (microVM + SEV-SNP z atestacją). Per-session izolacja: każda sesja Guacamole w osobnym kontenerze — eliminacja SPOF guacd. Wymagania: sesja P95 <3s nawiązanie, latencja <150ms one-way, jitter <30ms P95. Szyfrowanie: IPsec IKEv2 na warstwie transportowej jest wystarczające — broker działa wewnątrz chronionego środowiska TEE.

Model B — SFrame (RFC 9605) + WebRTC Insertable Streams [E]: Eksperymentalny model E2EE dla mediów audio/video. Ramki audio i wideo szyfrowane bezpośrednio na poziomie aplikacji przed wysłaniem — broker staje się ‘ślepy’ na treść mediów. Technologia: SFrame definiuje format szyfrowania ramek medialnych (nagłówkek KID + AES-GCM-128/256). Klucze negocjowane poza głównym kanałem — bezpośrednio z HSM/Secure Enclave urządzenia. Znane

ograniczenia: RFC 9605 §7.2 — brak uwierzytelniania per-nadawca (SFrame nie chroni przed złośliwym członkiem grupy). WebRTC Insertable Streams: pełne wsparcie wyłącznie w Chromium-based. SFrame NIE rozwiązuje E2EE dla remote desktop (rendering obrazu ekranu) — tylko dla kanałów audio/video.

Tabela decyzyjna — kiedy stosować który model: Remote workspace (dokumenty, CRM, przeglądarka) → Model A [N]. Wideokonferencje wewnętrzne (env-voice, env-matrix AV) → Model B [E] w środowiskach pilotażowych, Model A z per-session TEE w produkcji. VOIP głos → Model B [E] z SFrame+SRTP jako cel roadmapy. Full remote desktop E2EE pixel-level → brak produkcyjnej implementacji; wymaga własnego protokołu lub technologii klasy Hypori (roadmapa STATE-LEVEL).

Zgodność z Hypori: Hypori (FedRAMP High, DoD IL5) jest architektonicznym benchmarkiem. SYLION w modelu A osiąga ekwiwalentne właściwości bezpieczeństwa dla remote workspace przy użyciu per-session TEE. Model B SFrame jest ambicją przekraczającą Hypori dla kanałów AV — jednak wymaga dojrzałości [E]→[R] przed wdrożeniem produkcyjnym. Przejście SFrame z [E] do [R] wymaga: niezależnego audytu bezpieczeństwa SFrame implementation, walidacji RFC 9605 §7.2 mitigations, testów penetracyjnych środowiska pilotażowego, certyfikacji co najmniej [R] przed włączeniem do baseline PRO.

CZĘŚĆ VIII — ODPORNOŚĆ POSTKWANTOWA I STRATEGIA KRYPTOGRAFICZNA

Rozdział 72. Wprowadzenie do zagrożeń kwantowych

72.1 Zagrożenie harvest-now-decrypt-later — mechanizm, co już jest zbierane, horyzont

Status: [N] Normatywny Odbiorca: CISO, Architekt Bezpieczeństwa, Security Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.6, 73.1, 74.1

Atak typu harvest-now-decrypt-later (HNDL) polega na masowym przechwytywaniu zaszyfrowanego ruchu sieciowego przez przeciwnika dysponującego możliwościami państwowymi, z zamiarem odszyfrowania zgromadzonych danych w momencie uzyskania dostępu do kryptograficznie istotnego komputera kwantowego (CRQC — Cryptographically Relevant Quantum Computer). Mechanizm jest prosty: przeciwnik rejestruje szyfrogram przesyłany protokołami takimi jak TLS 1.3 czy IPsec IKEv2, przechowuje go w archiwach o dużej pojemności, a następnie — po upływie lat lub dekad — stosuje algorytm Shora do złamania wymiany kluczy opartej na RSA, ECDH lub ECDSA.

Zagrożenie HNDL jest realne i udokumentowane. Agencje wywiadowcze wielu państw prowadzą programy masowego przechwytywania ruchu na łączach międzynarodowych, punktach wymiany ruchu (IXP) oraz w infrastrukturze operatorów telekomunikacyjnych. W kontekście SYLION oznacza to, że sesje VPN (IPsec IKEv2) między terminalami operatorów a bramami G1/G2, ruch Matrix (federation i client-server API) oraz dane przesyłane do i z mikroVM mogą być przechwytywane już dziś.

Szczególnie narażone są następujące kategorie danych SYLION:

Sesje IKEv2 — wymiana kluczy oparta na ECDH (Curve25519 lub P-384) jest podatna na atak kwantowy; przechwycony handshake pozwala odtworzyć klucz sesyjny.

TLS 1.3 — wymiana kluczy X25519 lub P-256 w handshake TLS jest równie podatna.

Federacja Matrix — ruch między homeserverami, nawet zaszyfrowany TLS, może zawierać metadane korelowalne z tożsamościami operatorów.

Dane archiwalne — logi audytu, podpisane artefakty, certyfikaty PKI z kluczami RSA/ECDSA.

Horyzont zagrożenia HNDL wyznacza się wzorem Mossmanina: jeśli czas przechowywania danych wrażliwych (X lat) plus czas migracji kryptograficznej (Y lat) przekracza czas do pojawienia się CRQC (Z lat), to dane są zagrożone już teraz ($X + Y > Z$). Dla klientów STATE, gdzie dane mogą zachowywać wrażliwość przez 20–50 lat, a migracja kryptograficzna wymaga 3–5 lat, zagrożenie HNDL jest aktualne nawet przy optymistycznych prognozach pojawienia się CRQC w perspektywie 10–15 lat. Z tego powodu SYLION musi traktować HNDL jako zagrożenie wymagające natychmiastowego działania, a nie przyszłą hipotezę.

72.2 Wpływ na transport — VPN/TLS susceptibility, current SYLION exposure

Status: [N] Normatywny Odbiorca: Architekt Bezpieczeństwa, Network Engineer, DevOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.1, 73.6, 74.4, 74.5

Warstwa transportowa SYLION opiera się na dwóch fundamentalnych protokołach kryptograficznych: IPsec IKEv2 (tunele VPN między terminalami operatorów a bramami G1/G2) oraz TLS 1.3 (komunikacja aplikacyjna — Matrix, API zarządzania, telemetria). Oba protokoły w obecnej konfiguracji wykorzystują algorytmy wymiany kluczy podatne na atak kwantowy.

IPsec IKEv2 — ekspozycja bieżąca: Tunele IKEv2 w SYLION używają wymiany kluczy opartej na ECDH z krzywą Curve25519 (tier STANDARD/PRO) lub P-384 (tier STATE). Algorytm Shora pozwala na efektywne rozwiązanie problemu logarytmu dyskretnego na krzywych eliptycznych, co oznacza, że przechwycony handshake IKE_SA_INIT umożliwi w przyszłości odtworzenie klucza KEYSEED i odszyfrowanie całej sesji IPsec — włącznie z danymi ESP (Encapsulating Security Payload).

Kluczowe jest zrozumienie, że nawet jeśli klucze sesyjne są efemeryczne (PFS — Perfect Forward Secrecy), to PFS chroni jedynie przed kompromitacją klucza długoterminowego przy użyciu klasycznych komputerów. Komputer kwantowy łamiący ECDH w IKE_SA_INIT uzyskuje klucz sesyjny bezpośrednio z przechwyconego handshake, czyniąc PFS nieskutecznym w scenariuszu kwantowym.

TLS 1.3 — ekspozycja bieżąca: Komunikacja Matrix (client-server API na portach 443/8448, federation API), interfejs zarządzania SYLION oraz telemetria wykorzystują TLS 1.3 z wymianą kluczy X25519 lub P-256. Podatność jest analogiczna jak w przypadku IKEv2 — przechwycony ClientHello/ServerHello z KeyShare pozwala komputerowi kwantowemu odtworzyć shared secret.

Ocena ekspozycji: SYLION stosuje szyfrowanie symetryczne AES-256-GCM zarówno w ESP (IPsec), jak i w rekordach TLS. AES-256 jest odporny na ataki kwantowe (algorytm Grovera redukuje efektywną siłę klucza do 128 bitów, co pozostaje bezpieczne). Zagrożenie kwantowe dotyczy wyłącznie wymiany kluczy asymetrycznych — ale to właśnie wymiana kluczy determinuje bezpieczeństwo całej sesji. Przechwycenie handshake i złamanie wymiany kluczy daje dostęp do kluczy symetrycznych użytych w sesji.

Wniosek: migracja transportu do hybrydowych wymian kluczy (klasyczna + PQC) jest priorytetem zerowym w strategii odporności postkwantowej SYLION.

72.3 Wpływ na PKI — certificate validity periods, quantum-vulnerable key types

Status: [N] Normatywny Odbiorca: Architekt Bezpieczeństwa, PKI Administrator, CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.5, 73.2, 73.3, 74.6

Infrastruktura klucza publicznego (PKI) SYLION stanowi fundament zaufania w całym systemie. Certyfikaty X.509 są używane do uwierzytelniania bramek G1/G2, terminali operatorów, serwerów Matrix, komponentów zarządzania oraz do podpisywania artefaktów (kod, polityki, logi audytu). Wszystkie te certyfikaty opierają się na algorytmach podpisu cyfrowego podatnych na atak kwantowy.

Typy kluczy podatnych na atak kwantowy w PKI SYLION:

RSA-2048/4096 — używane w starszych certyfikatach CA i certyfikatach serwerowych. Algorytm Shora faktoryzuje klucz RSA w czasie wielomianowym. RSA-2048 wymaga ~4099 kubitów logicznych, RSA-4096 ~8194 kubitów logicznych.

ECDSA P-256/P-384 — podpisy certyfikatów w bieżącej konfiguracji SYLION. Algorytm Shora rozwiązuje problem logarytmu dyskretnego na krzywych eliptycznych. P-256 wymaga ~2330 kubitów logicznych.

Ed25519 — wariant EdDSA na krzywej Curve25519, używany w podpisach Matrix (Olm/Megolm) i potencjalnie w certyfikatach wewnętrznych. Równie podatny jak ECDSA.

Okresy ważności certyfikatów a ryzyko kwantowe: Root CA SYLION ma okres ważności 20 lat, pośrednie CA 10 lat, certyfikaty serwerowe 1 rok, certyfikaty klienckie (terminale) 90 dni–1 rok. Z perspektywy HNDL kluczowy jest nie okres ważności certyfikatu, lecz okres, przez jaki podpis musi pozostać wiarygodny. Podpisy na logach audytu, podpisy kodu źródłowego, podpisy polityk bezpieczeństwa — te artefakty muszą być weryfikowalne przez lata po wygaśnięciu certyfikatu.

Scenariusze ataku na PKI:

Falszowanie certyfikatów — komputer kwantowy może wygenerować klucz prywatny odpowiadający kluczowi publicznemu CA, umożliwiając emisję fałszywych certyfikatów.

Retroaktywna kompromitacja podpisów — podpisy złożone kluczami ECDSA/RSA mogą zostać sfalszowane post factum, podważając integralność logów audytu i artefaktów.

Atak na łańcuch zaufania — złamanie jednego ogniwa w hierarchii CA kompromituje wszystkie certyfikaty podrzędne.

Migracja PKI do algorytmów postkwantowych (ML-DSA, SLH-DSA) jest krytyczna, ale bardziej złożona niż migracja transportu, ponieważ wymaga ceremonii kluczy, aktualizacji łańcuchów zaufania i zachowania kompatybilności wstecznej w okresie przejściowym.

72.4 Wpływ na archiwalne dane — long-lived data at risk, what SYLION holds

Status: [N] Normatywny Odbiorca: CISO, Data Protection Officer, Compliance Officer Wpływ na baseline: Wysoki Powiązane rozdziały: 72.1, 72.3, 84.1

SYLION jako platforma bezpiecznej komunikacji i pracy zdalnej przetwarza oraz przechowuje dane o zróżnicowanym okresie wrażliwości. Architektura Zero Trust i end-to-end encryption (E2EE) w warstwie Matrix ogranicza ekspozycję treści komunikacji, ale nie eliminuje ryzyka kwantowego dla wszystkich kategorii danych.

Dane przechowywane przez SYLION i ich okres wrażliwości:

Kategoria danych	Przechowywanie	Okres wrażliwości	Ryzyko HNDL
Treści komunikacji (E2EE Matrix)	Zaszyfrowane kluczami Megolm, przechowywane na homeserverze	10–50 lat (zależnie od klienta)	Wysokie — klucze sesyjne Megolm wymieniane przez Olm (X25519) podatne na atak kwantowy
Logi audytu (Zone 4)	Podpisane, przechowywane 5–10 lat	5–20 lat	Średnie — integralność podpisów ECDSA zagrożona
Polityki bezpieczeństwa	Wersjonowane, podpisane	Czas życia polityki	Niskie–Średnie
Certyfikaty PKI	Przechowywane w rejestrze	1–20 lat	Wysokie — klucze prywatne CA
Konfiguracje IaC	Wersjonowane w Git, podpisane	3–5 lat	Niskie
Definicje środowisk operatorów	Przechowywane w bazie zarządzania	Czas życia tenanta	Niskie
Klucze sesyjne (efemeryczne)	Nie przechowywane	Brak	Brak (ale przechwycone w transzycie — ryzyko HNDL)

Kluczowe obserwacje dla SYLION:

Treści komunikacji stanowią najwyższe ryzyko. Choć SYLION nie przechowuje kluczy w plaintext, przechwycony ruch Matrix (szyfrogramy Megolm + wymiana kluczy Olm) pozwala komputerowi kwantowemu na odtworzenie kluczy sesyjnych i odszyfrowanie wiadomości.

Logi audytu są drugim priorytetem — ich integralność opiera się na podpisach ECDSA/Ed25519, które komputer kwantowy może sfalszować.

Dane o wartości wywiadowczej — dla klientów STATE komunikacja może dotyczyć spraw bezpieczeństwa narodowego, dyplomacji, infrastruktury krytycznej. Okres wrażliwości takich danych to 25–50 lat, co czyni je najbardziej narażonymi na atak HNDL.

Architektura SYLION musi zapewnić, że nowe sesje komunikacyjne są chronione algorytmami postkwantowymi (ochrona forward secrecy), nawet jeśli dane archiwalne pozostaną narażone do czasu pełnej migracji PKI.

72.5 Wpływ na HSM — HSM quantum readiness, key types stored

Status: [N] Normatywny Odbiorca: Architekt Bezpieczeństwa, PKI Administrator, HSM Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 75.1, 75.2, 75.6

Sprzętowe moduły bezpieczeństwa (HSM) stanowią rdzeń zaufania kryptograficznego SYLION. HSM przechowują klucze prywatne CA (Root CA, Intermediate CA), wykonują operacje podpisu cyfrowego, generują klucze efemeryczne i zabezpieczają ceremonie kluczy. Gotowość HSM na erę postkwantową determinuje tempo migracji PQC całego systemu.

Typy kluczy obecnie przechowywanych w HSM SYLION:

Klucze Root CA — RSA-4096 lub ECDSA P-384, okres życia 20 lat. Złamanie klucza Root CA kompromituje cały łańcuch zaufania.

Klucze Intermediate CA — ECDSA P-384, okres życia 10 lat.

Klucze podpisu kodu — ECDSA P-256 lub P-384, rotowane co 2 lata.

Klucze podpisu logów audytu — ECDSA P-256, rotowane co 1 rok.

Klucze szyfrowania kopii zapasowych — AES-256 (odporny na atak kwantowy) opakowywany kluczem RSA lub ECDH (podatny).

Gotowość HSM na PQC — stan obecny:

Stan wsparcia algorytmów PQC w dostępnych komercyjnie HSM (stan na 2026):

Producent	Model	ML-KEM	ML-DSA	SLH-DSA	FIPS 140-3 L3
Utimaco	CryptoServer Se Gen2	Tak (firmware 5.x+)	Tak	Planowane	Tak

Thales	Luna Network HSM 7	Tak (firmware 7.4+)	Tak	Planowane	Tak
Entrust	nShield XC	Częściowe	Częściowe	Nie	Tak
AWS	CloudHSM	Nie (PQC via SDK)	Nie	Nie	Tak (Level 3)

Wyzwania dla SYLION:

- Migracja kluczy Root CA — wygenerowanie nowego klucza PQC Root CA wymaga ceremonii kluczy w środowisku air-gapped z HSM wspierającym ML-DSA. Istniejące klucze nie mogą być „uaktualnione” — konieczna jest emisja nowego certyfikatu Root CA.
- Wydajność — operacje ML-DSA w HSM są wolniejsze niż ECDSA (podpis ML-DSA-65: ~2–5 ms vs ECDSA P-384: <1 ms). Przy dużej liczbie operacji podpisu (logi audytu, certyfikaty krótkoterminowe) konieczne jest planowanie pojemności.
- Key wrapping — opakowywanie kluczy symetrycznych kluczem PQC (ML-KEM) wymaga zmiany procedur eksportu/importu kluczy między HSM.
- Aktualizacja firmware — nie wszystkie HSM wspierają aktualizację firmware do wersji z PQC bez wymiany sprzętu. Konieczna jest inwentaryzacja i planowanie wymiany.
- HSM muszą być traktowane jako element krytycznej ścieżki migracji PQC — brak wsparcia PQC w HSM blokuje migrację PKI.

72.6 Horyzont czasowy ryzyka — cryptographically relevant quantum computer timeline

- Status: [N] Normatywny Odbiorca: CISO, Zarząd, Architekt Bezpieczeństwa Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.1, 72.7, 74.3
- Oszacowanie momentu pojawienia się kryptograficznie istotnego komputera kwantowego (CRQC) jest obarczone dużą niepewnością, ale instytucje regulacyjne i wywiadowcze formułują prognozy, na których SYLION musi oprzeć swoją strategię.
- Prognozy instytucjonalne:
- NIST — wskazuje na konieczność natychmiastowej migracji, zakładając że CRQC może pojawić się w perspektywie 10–20 lat (2034–2044), ale przygotowania muszą rozpocząć się teraz ze względu na czas trwania migracji.
- NSA/CISA — CNSA 2.0 wymaga wsparcia algorytmów PQC w nowych systemach NSS do 2027 r. i wyłącznego użycia PQC do 2030–2031 r. dla sprzętu sieciowego. Harmonogram zakłada, że zagrożenie jest wystarczająco realne, by uzasadnić migrację wyprzedzającą.
- BSI (Niemcy) — rekomenduje hybrydowe podejście (klasyczne + PQC) od 2025 r.
- ANSSI (Francja) — analogiczne rekomendacje, z naciskiem na crypto-agility.
- Harmonogram CNSA 2.0 — kluczowe daty:

Data	Wymaganie
2025	Preferowane użycie CNSA 2.0 dla podpisów oprogramowania/firmware
2026	Preferowane użycie CNSA 2.0 dla sprzętu sieciowego (VPN, routery)
1 stycznia 2027	Wszystkie nowe akwizycje NSS muszą być zgodne z CNSA 2.0
31 grudnia 2030	Wyłączne użycie CNSA 2.0 dla podpisów oprogramowania i sprzętu sieciowego
31 grudnia 2031	Pełne wymuszenie — wszystkie implementacje kryptograficzne w NSS muszą używać algorytmów CNSA 2.0
2033	Aplikacje niestandardowe i sprzęt legacy — CNSA 2.0 wyłącznie
2035	NIST — proponowana data zakazu kryptografii podatnej na atak kwantowy

Implikacje dla SYLION:

- Tier STATE obsługuje klientów rządowych i instytucje bezpieczeństwa narodowego, dla których CNSA 2.0 jest mandatowe. Oznacza to, że SYLION STATE musi: - Do 2026: oferować hybrydowy transport PQC (IKEv2 z ML-KEM + ECDH). - Do 2027: być w pełni zgodny z CNSA 2.0 dla nowych wdrożeń. - Do 2030: wyłącznie PQC dla transportu sieciowego.
- Tier PRO powinien oferować hybrydowe PQC jako opcję od 2026, z obowiązkiem od 2027. Tier STANDARD może pozostać przy klasycznej kryptografii z opcją hybrydową, ale roadmapa musi uwzględniać pełną migrację do 2030.

72.7 Krytyczność dla SYLION — STATE tier clients face state-level adversaries

- Status: [N] Normatywny Odbiorca: CISO, Product Owner, Zarząd, Architekt Bezpieczeństwa Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.1–72.6, 73.7, 74.3
- Analiza zagrożeń kwantowych musi być interpretowana w kontekście profilu klientów SYLION i poziomu przeciwników, z jakimi ci klienci się mierzą.
- Tier STATE (2500 €/użytkownik/miesiąc, min. 50 użytkowników): Klienci STATE to instytucje rządowe, agencje bezpieczeństwa, służby dyplomatyczne, operatorzy infrastruktury krytycznej. Ich przeciwnikami są państwowe programy wywiadu sygnałowego (SIGINT) dysponujące: - Masową infrastrukturą przechwytywania ruchu na łączach międzynarodowych. - Budżetami na przechowywanie petabajtów szyfrogramów przez dekady. - Priorytetowym dostępem do przyszłych komputerów kwantowych.
- Dla tych klientów HNDL nie jest hipotezą — to operacyjna rzeczywistość. Komunikacja prowadzona dziś przez SYLION STATE może zawierać informacje wrażliwe przez 25–50 lat. Brak ochrony PQC w warstwie transportu oznacza, że każda sesja IKEv2 i TLS przechwycona dziś może zostać odszyfrowana w przyszłości.
- Tier PRO (1500 €/użytkownik/miesiąc): Klienci PRO to organizacje korporacyjne, kancelarie prawne, firmy konsultingowe, instytucje finansowe. Ich przeciwnikami mogą być zarówno państwowe programy wywiadu gospodarczego, jak i zorganizowane grupy cyberprzestępcze z zaawansowanymi możliwościami. Okres wrażliwości danych: 5–15 lat. Ryzyko HNDL jest realne, choć mniej pilne niż dla STATE.
- Tier STANDARD (400 €/użytkownik/miesiąc): Klienci STANDARD to firmy średniej wielkości, zespoły zdalne, organizacje wymagające bezpiecznej komunikacji bez rygoru regulacyjnego. Przeciwnicy to głównie cyberprzestępcy i konkurencja. Ryzyko HNDL jest ograniczone — dane rzadko zachowują wrażliwość powyżej 5 lat, a

przeciwnicy prawdopodobnie nie będą mieli wczesnego dostępu do CRQC.

Matryca priorytetów migracji PQC:

Tier	Transport PQC	PKI PQC	Priorytet	Termin
STATE	Wymagany natychmiast	Wymagany 2027	Krytyczny	2026–2027
PRO	Hybrydowy obowiązkowy	Hybrydowy 2027	Wysoki	2026–2028
STANDARD	Opcjonalny 2026, obowiązkowy 2028	2028–2030	Średni	2028–2030

SYLION musi zapewnić, że migracja PQC nie jest traktowana jako jednolity projekt, lecz jako strategia zróżnicowana per tier, z priorytetem absolutnym dla STATE.

Katalog ataków — macierz szybkiego przeglądu

Atak	Skutek bez ochrony	Środki ochronne	Ryzyko rezydualne
Kradzież/konfiskata terminala	Dostęp do aktywnej sesji i danych	GrapheneOS BFU auto-reboot 18h, FIDO2 Heartbeat 8h, brak lokalnych danych	Bardzo niskie — terminal jest pusty
Wymuszenie hasła (duress)	Ujawnienie dostępu do G1/G2/VPS	Dead Man Switch 72h, Duress PIN wipe kluczy, Separation of Duties	Niskie — środowisko zostaje zniszczone
IMSI Catcher / fałszywy BTS	Przechwycenie pakietów, downgrade GSM	Kill switch VPN, data-only SIM, rotacja IMSI [A], Starlink bypass	Niskie — ruch = zaszyfrowany szum
SS7 / Diameter attack	Przechwycenie SMS, lokalizacja	Brak voice/SMS (data-only SIM), cały ruch przez IPsec	Bardzo niskie — brak wektora SS7
0-day w złośliwym załączniku	Infekcja środowiska komunikatora	CDR pipeline OPSWAT Deep CDR, staging G2, microVM izolacja	Niskie — wirus w izolowanym env
Lateral movement między operatorami	Kompromitacja operatora B przez A	Mikrosegmentacja Zero Trust, osobne VPS/subnet per operator	Bardzo niskie — fizyczna izolacja sieciowa
Kompromitacja Session Broker (RCE)	Dostęp do sesji wszystkich operatorów	Per-session izolacja kontener/microVM, alternatywa: Keeper CM	Niskie przy per-session; Wysokie przy guacd współdzielonym
Memory scraping klucza (hypervisor)	Wyciąg kluczy kryptograficznych z RAM	AMD SEV-SNP / Intel TDX szyfrowanie pamięci, atestacja przed sekretem	Niskie po wdrożeniu TEE
Rekwizycja serwera / MLAT	Dostęp do danych operatorów	Alpine diskless RAM-only, szyfrowanie at-rest, Jurisdictional Hopping [A]	Bardzo niskie — dysk = zaszyfrowany szum lub pusty
DDoS na G1	Zablokowanie dostępu operatorów	Rate limiting, rotacja IP/ASN (IaC), failover CDN	Średnie dla dostępności; Niskie dla danych
Supply chain — złośliwy obraz bazowy	Backdoor w workloadzie operatora	Immutable infrastructure, pinowanie wersji, verification pipeline, SBOM	Rezydualne — najtrudniejszy wektor
Podsłuch sesji AV (wideokonferencja)	Przechwycenie treści rozmowy	SFrame RFC 9605 [E] + IPsec transport, per-session TEE dla brokera	Niskie dla AV przy SFrame; Niskie dla desktop przy TEE

Rozdział 73. Quantum-safe kryptografia i algorytmy rekomendowane

73.1 ML-KEM (FIPS 203 / Kyber) — key encapsulation

Status: [N] Normatywny Odbiorca: Architekt Bezpieczeństwa, Security Engineer, Kryptograf Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.2, 74.4, 74.5, 75.3

UWAGA: Status standaryzacji ML-KEM w IPsec. draft-ietf-ipsecme-ikev2-mlkem (ML-KEM w IKEv2) jest nadal dokumentem IETF Internet-Draft, NIE opublikowanym RFC. strongSwan 6.0 oferuje wsparcie ML-KEM przez liboqs (Open Quantum Safe), ale jest to wsparcie eksperymentalne, nie production-certified. Produkcyjne wdrożenie PQC w IPsec wymaga: (1) walidacji interoperacyjności z innymi implementacjami IKEv2, (2) testów wydajnościowych (ML-KEM-1024 dodaje ~15-20ms do handshake), (3) walidacji CAVP po finalizacji RFC. Do czasu publikacji RFC, PQC w IPsec powinien być traktowany jako [R] Rekomendowany dla STATE, nie [N] Normatywny.

ML-KEM (Module-Lattice-based Key-Encapsulation Mechanism), opublikowany jako FIPS 203 przez NIST w sierpniu 2024, jest postkwantowym mechanizmem enkapsulacji klucza opartym na problemie Module Learning with Errors (MLWE). ML-KEM zastępuje podatne na atak kwantowy mechanizmy wymiany kluczy (ECDH, DH) i stanowi fundament strategii ochrony transportu SYLION.

Zestawy parametrów ML-KEM:

Parametr	Poziom bezpieczeństwa	Klucz publiczny	Szyfrogram	Klucz współdzielony	Zastosowanie SYLION
ML-KEM-512	NIST Level 1 (~AES-128)	800 B	768 B	32 B	Niezalecany (zbyt niski poziom)
ML-KEM-768	NIST Level 3 (~AES-192)	1184 B	1088 B	32 B	PRO — hybrydowy transport
ML-KEM-1024	NIST Level 5 (~AES-256)	1568 B	1568 B	32 B	STATE — transport i PKI

Zastosowania ML-KEM w SYLION:

IKEv2 Hybrid Key Exchange — ML-KEM jest używany jako dodatkowy mechanizm wymiany kluczy w IKEv2 zgodnie z RFC 9370 (Multiple Key Exchanges in IKEv2). W handshake IKE_SA_INIT negocjowana jest klasyczna wymiana ECDH (Curve25519 lub P-384), a następnie w serii wymian IKE_INTERMEDIATE wykonywana jest enkapsulacja ML-KEM. Wynikowy shared secret łączy oba materiały kryptograficzne — bezpieczeństwo jest zachowane, jeśli choćby jeden z mechanizmów pozostaje nienaruszony.

TLS 1.3 Hybrid Key Exchange — ML-KEM jest używany w hybrydowych grupach kluczy TLS 1.3. Klient i serwer negocjują grupę hybrydową (np. X25519_ML-KEM-768 lub P-384_ML-KEM-1024) w rozszerzeniu supported_groups. Wymiana kluczy odbywa się w jednym roundtrip (KeyShare z połączonym kluczem publicznym).

Key Wrapping w HSM — ML-KEM może być używany do enkapsulacji kluczy symetrycznych podczas eksportu/importu między HSM.

Wydajność: Generowanie pary kluczy ML-KEM-768: ~30 μs, enkapsulacja: ~40 μs, dekapulacja: ~35 μs (CPU Xeon Gen 4, bez akceleracji). Narzut na handshake IKEv2 z hybrydowym ML-KEM-768: ~15 ms (głównie z powodu większych pakietów i dodatkowej rundy wymiany), co jest akceptowalne dla wszystkich tierów SYLION.

73.2 ML-DSA (FIPS 204 / Dilithium) — digital signatures

Status: [N] Normatywny Odbiorca: Architekt Bezpieczeństwa, PKI Administrator, Security Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.3, 74.6, 75.4

ML-DSA (Module-Lattice-based Digital Signature Algorithm), opublikowany jako FIPS 204 przez NIST w sierpniu 2024, jest postkwantowym algorytmem podpisu cyfrowego opartym na problemie Module Learning with Errors (MLWE). ML-DSA zastępuje podatne na atak kwantowy algorytmy podpisu (RSA, ECDSA, EdDSA) i stanowi główny algorytm podpisu cyfrowego w strategii PQC SYLION.

Zestawy parametrów ML-DSA:

Parametr	Poziom bezpieczeństwa	Klucz publiczny	Podpis	Zastosowanie SYLION
ML-DSA-44	NIST Level 2 (~AES-128+)	1312 B	2420 B	Niezalecany
ML-DSA-65	NIST Level 3 (~AES-192)	1952 B	3293 B	PRO — certyfikaty, podpisy
ML-DSA-87	NIST Level 5 (~AES-256)	2592 B	4595 B	STATE — certyfikaty, podpisy

Zastosowania ML-DSA w SYLION:

Podpisy certyfikatów PKI — Intermediate CA i End Entity certificates podpisywane ML-DSA. W okresie przejściowym stosowane są certyfikaty hybrydowe (dual-signature: ECDSA + ML-DSA) dla zachowania kompatybilności.

Podpis kodu (Code Signing) — artefakty kompilacji (kontenery, obrazy Firecracker, firmware terminali) podpisywane ML-DSA. Weryfikacja podpisu przed deploy w pipeline CI/CD.

Podpis logów audytu — wpisy w logach Zone 4 podpisywane ML-DSA dla zapewnienia integralności post-quantowej. Kluczowe dla klientów STATE, gdzie logi mogą być dowodem w procedurach prawnych przez dekady.

Podpis polityk bezpieczeństwa — deklaratywne polityki OPA/Rego podpisywane ML-DSA przed wdrożeniem, uniemożliwiając modyfikację polityk przez przeciwnika.

Uwierzelnianie IKEv2 — podpisy AUTH payload w IKEv2 mogą używać ML-DSA zamiast RSA/ECDSA, zapewniając postkwantowe uwierzelnianie tuneli VPN.

Wydajność: Generowanie klucza ML-DSA-65: ~100 μs, podpis: ~200 μs, weryfikacja: ~80 μs. Podpisy ML-DSA są znacznie większe niż ECDSA (3293 B vs 64 B), co wpływa na rozmiar certyfikatów i pakietów sieciowych, ale nie stanowi ograniczenia dla przepływów SYLION.

CNSA 2.0: CNSA 2.0 zaleca ML-DSA-87 dla systemów NSS. SYLION STATE musi używać ML-DSA-87, PRO może używać ML-DSA-65.

73.3 SLH-DSA (FIPS 205 / SPHINCS+) — hash-based signatures

Status: [R] Rekomendowany Odbiorca: Architekt Bezpieczeństwa, PKI Administrator Wpływ na baseline: Średni Powiązane rozdziały: 72.3, 74.6, 75.5

SLH-DSA (Stateless Hash-Based Digital Signature Algorithm), opublikowany jako FIPS 205 przez NIST w sierpniu 2024, jest postkwantowym algorytmem podpisu cyfrowego opartym wyłącznie na funkcjach skrótu (hash-based). W odróżnieniu od ML-DSA, SLH-DSA nie opiera się na problemach kratownicowych (lattice), lecz na bezpieczeństwie funkcji skrótu — co daje dodatkową dywersyfikację kryptograficzną.

Charakterystyka SLH-DSA:

Cecha	Wartość
Bezpieczeństwo	Oparte wyłącznie na funkcjach hash (SHA-256, SHAKE)
Podpis	7856 B – 49856 B (zależnie od parametru)
Klucz publiczny	32 B – 64 B
Czas podpisu	~10–100 ms (wolniejszy niż ML-DSA)
Czas weryfikacji	~5–15 ms

Zalety SLH-DSA: - Bezpieczeństwo oparte na innej fundamentalnej prymitywie kryptograficznej niż ML-DSA. Jeśli problem MLWE okaże się słabszy niż zakładano (atak na kratki), SLH-DSA pozostaje bezpieczny. - Bezstanowość — w odróżnieniu od LMS/XMSS nie wymaga śledzenia stanu, co upraszcza wdrożenie. - Konserwatywna baza bezpieczeństwa — zaufanie do funkcji hash jest znacznie silniejsze niż do problemów kratownicowych.

Zastosowania SLH-DSA w SYLION:

Root CA — certyfikat Root CA podpisany SLH-DSA jako alternatywa lub uzupełnienie ML-DSA. Root CA jest używany rzadko (emisja Intermediate CA), więc narzut wydajnościowy jest akceptowalny. Dywersyfikacja algorytmiczna Root CA zwiększa odporność na przełomowe ataki.

Podpisy długoterminowe — artefakty wymagające weryfikacji przez 20+ lat (np. kluczowe kontrakty, polityki bazowe) mogą być podpisywane SLH-DSA dla maksymalnej pewności.

Backup signatures — dual-sign artefaktów krytycznych: ML-DSA (szybki, operacyjny) + SLH-DSA (konserwatywny, długoterminowy).

Ograniczenia: - Duży rozmiar podpisu (do 49 KB) wyklucza użycie w protokołach sieciowych o ograniczonej przepustowości. - Wolniejszy czas podpisu uniemożliwia użycie w scenariuszach wymagających dużej przepustowości (logi audytu generowane masowo). - CNSA 2.0 explicite nie uwzględnia SLH-DSA — preferuje LMS/XMSS dla podpisów stanowych i ML-DSA dla podpisów bezstanowych. SYLION używa SLH-DSA jako opcji dywersyfikacyjnej, nie jako wymóg CNSA 2.0.

73.4 AES-256 — quantum-resistant symmetric cipher

Status: [N] Normatywny Odbiorca: Architekt Bezpieczeństwa, Security Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.2, 73.5

AES-256 (Advanced Encryption Standard z kluczem 256-bitowym) pozostaje fundamentalnym algorytmem szyfrowania symetrycznego w architekturze SYLION i jest odporny na znane ataki kwantowe.

Odporność kwantowa AES-256: Algorytm Grovera — jedyny znany atak kwantowy na szyfry symetryczne — zapewnia kwadratowe przyspieszenie wyszukiwania klucza brute-force. Dla AES-256 oznacza to redukcję efektywnej siły klucza z 2^{256} do 2^{128} operacji kwantowych, co pozostaje poza zasięgiem obliczeń nawet z uwzględnieniem optymistycznych prognoz rozwoju komputerów kwantowych. AES-128, z efektywną siłą 2^{64} po ataku Grovera, jest uważany za niewystarczający w perspektywie postkwantowej.

Zastosowania AES-256 w SYLION:

ESP (IPsec) — szyfrowanie danych w tunelach IPsec: AES-256-GCM (Galois/Counter Mode) zapewniający poufność i integralność.

TLS 1.3 — szyfrowanie rekordów TLS: AES-256-GCM jako preferowany cipher suite.

Szyfrowanie danych at rest — dyski, backupy, archiwa: AES-256-XTS (dla dysków) lub AES-256-GCM.

Key wrapping — opakowywanie kluczy w HSM: AES-256-KWP (Key Wrap with Padding).

E2EE Matrix (Megolm) — szyfrowanie wiadomości AES-256-CTR (w ramach protokołu Megolm).

Wymagania per tier:

Tier	Wymagany szyfr symetryczny	Tryb
STANDARD	AES-256-GCM	Obowiązkowy
PRO	AES-256-GCM	Obowiązkowy
STATE	AES-256-GCM	Obowiązkowy, CNSA 2.0

AES-256 jest jedynym dozwolonym szyfrem symetrycznym w SYLION. ChaCha20-Poly1305, choć bezpieczny, nie jest zatwierdzony w CNSA 2.0 i nie jest wspierany przez wszystkie HSM z certyfikacją FIPS 140-3. SYLION standaryzuje na AES-256-GCM dla uproszczenia audytu i zgodności regulacyjnej.

Uwaga implementacyjna: Przejście na AES-256 (z ewentualnego AES-128 w starszych komponentach) nie wymaga zmian architektonicznych — jedynie aktualizację konfiguracji cipher suite i regenerację kluczy.

73.5 SHA-384/512 — quantum-resistant hash functions

Status: [N] Normatywny Odbiorca: Architekt Bezpieczeństwa, Security Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 73.4, 73.2

Funkcje skrótu kryptograficznego SHA-384 i SHA-512 (rodzina SHA-2) są odporne na znane ataki kwantowe i stanowią bazowe funkcje hash w architekturze SYLION.

Odporność kwantowa SHA-2: Algorytm Grovera redukuje bezpieczeństwo funkcji hash z n-bitowym wyjściem do n/2 bitów w scenariuszu wyszukiwania drugiego praobrazu (second preimage). SHA-256 z efektywnym bezpieczeństwem 128 bitów po ataku Grovera jest wystarczający, ale SYLION standaryzuje na SHA-384 (efektywne 192 bity po Groverze) i SHA-512 (efektywne 256 bitów) dla dodatkowego marginesu bezpieczeństwa i zgodności z CNSA 2.0, która wymaga SHA-384 jako minimum.

Zastosowania w SYLION:

IKEv2 PRF — Pseudo-Random Function w IKEv2 oparta na HMAC-SHA-384 lub HMAC-SHA-512.

TLS 1.3 — algorytm hash w handshake i HKDF: SHA-384.

Podpisy certyfikatów — algorytm hash w podpisie: SHA-384 (z ECDSA) lub SHA-512 (z ML-DSA).

Integralność logów audytu — łańcuch hash (hash chain) oparty na SHA-512.

SBOM i artefakty — sumy kontrolne artefaktów: SHA-384 lub SHA-512.

HSM key derivation — funkcje KDF oparte na HMAC-SHA-512.

Wymagania per tier:

Tier	Minimalna funkcja hash	Uwagi
STANDARD	SHA-256 (SHA-384 zalecany)	SHA-256 wystarczający, ale migracja do SHA-384 zalecana
PRO	SHA-384	Obowiązkowy od 2026
STATE	SHA-384 (SHA-512 dla kluczowych operacji)	CNSA 2.0 wymaga SHA-384+

SHA-1 i MD5 są bezwzględnie zabronione w jakimkolwiek zastosowaniu kryptograficznym SYLION. SHA-256 jest dozwolony w tierze STANDARD, ale polityka standaryzacji SYLION preferuje SHA-384/512 dla jednolitości i przygotowości postkwantowej.

73.6 Hybrydowe profile — X25519 + ML-KEM-768 dla PRO, P-384 + ML-KEM-1024 dla STATE

Status: [N] Normatywny Odbiorca: Architekt Bezpieczeństwa, Network Engineer, Security Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 73.1, 74.4, 74.5

Podejście hybrydowe łączy klasyczny algorytm wymiany kluczy z algorytmem postkwantowym, zapewniając bezpieczeństwo tak długo, jak choćby jeden z mechanizmów jest nienaruszony. Jest to strategia zalecana przez NIST, BSI, ANSSI i wymagana przez CNSA 2.0 w okresie przejściowym.

Profil hybrydowy PRO — X25519 + ML-KEM-768:

Element	Algorytm	Uzasadnienie
Wymiana kluczy (IKEv2)	ECDH Curve25519 + ML-KEM-768 (via RFC 9370 ADD_KE)	Curve25519 — wydajny, dobrze zbadany; ML-KEM-768 — NIST Level 3

Wymiana kluczy (TLS 1.3)	X25519_MLKEM768 (hybrydowa grupa)	Jedna runda handshake, minimalne opóźnienie
Podpis certyfikatów	ECDSA P-256 + ML-DSA-65 (dual-signature)	Kompatybilność z istniejącymi klientami + ochrona PQC
Szyfr symetryczny	AES-256-GCM	Odporny na Grovera
Hash	SHA-384	CNSA 2.0 minimum
PRF (IKEv2)	HMAC-SHA-384	—

Profil hybrydowy STATE — P-384 + ML-KEM-1024:

Element	Algorytm	Uzasadnienie
Wymiana kluczy (IKEv2)	ECDH P-384 + ML-KEM-1024 (via RFC 9370 ADD_KE)	P-384 — CNSA 2.0 krzywa; ML-KEM-1024 — NIST Level 5
Wymiana kluczy (TLS 1.3)	P384_MLKEM1024 (hybrydowa grupa)	Wyższy poziom bezpieczeństwa
Podpis certyfikatów	ECDSA P-384 + ML-DSA-87 (dual-signature)	CNSA 2.0 compliant
Szyfr symetryczny	AES-256-GCM	CNSA 2.0
Hash	SHA-384	CNSA 2.0
PRF (IKEv2)	HMAC-SHA-384	—

Mechanizm hybrydowej wymiany kluczy w IKEv2 (RFC 9370): 1. IKE_SA_INIT — klasyczna wymiana ECDH (Curve25519 lub P-384). 2. IKE_INTERMEDIATE #1 — wymiana ML-KEM (KE payload z enkapsulacją ML-KEM-768/1024). 3. Derivation — SKEYSEED = PRF(Ni | Nr, klasyczny_shared_secret | PQC_shared_secret). 4. Wynikowy klucz jest bezpieczny, jeśli choćby jeden ze shared secrets jest nienaruszony.

Narzut wydajnościowy: Hybrydowy handshake IKEv2 z ML-KEM-768 dodaje ~15 ms do ustanowienia tunelu (dodatkowa runda IKE_INTERMEDIATE + enkapsulacja). Dla ML-KEM-1024 narzut wynosi ~18–20 ms. Po ustanowieniu tunelu przepustowość ESP nie zmienia się (AES-256-GCM). Narzut jest jednorazowy per tunnel setup/rekey i nie wpływa na doświadczenie użytkownika.

73.7 Profile dla różnych tierów — STANDARD, PRO, STATE

Status: [N] Normatywny Odbiorca: Product Owner, Architekt Bezpieczeństwa, Pre-sales Wpływ na baseline: Krytyczny Powiązane rozdziały: 73.6, 72.7, 74.3

Profil kryptograficzny per tier definiuje obowiązkowe, rekomendowane i opcjonalne algorytmy dla każdego poziomu usługi SYLION. Profile uwzględniają poziom zagrożeń, wymagania regulacyjne i możliwości wydajnościowe.

TIER STANDARD (400 €/użytkownik/miesiąc):

Warstwa	Bieżący profil (2026)	Docelowy profil (2028+)
IKEv2 Key Exchange	ECDH Curve25519	X25519 + ML-KEM-768 (hybrydowy)
TLS 1.3 Key Exchange	X25519	X25519_MLKEM768
Podpisy certyfikatów	ECDSA P-256	ECDSA P-256 + ML-DSA-65
Szyfr symetryczny	AES-256-GCM	AES-256-GCM
Hash	SHA-256 (SHA-384 zalecany)	SHA-384
HSM	FIPS 140-3 Level 2	FIPS 140-3 Level 2 z PQC

Status PQC: opcjonalny od 2026, obowiązkowy od 2028.

TIER PRO (1500 €/użytkownik/miesiąc):

Warstwa	Profil od 2026
IKEv2 Key Exchange	X25519 + ML-KEM-768 (hybrydowy, obowiązkowy)
TLS 1.3 Key Exchange	X25519_MLKEM768 (obowiązkowy)
Podpisy certyfikatów	ECDSA P-256 + ML-DSA-65 (dual-signature)
Szyfr symetryczny	AES-256-GCM
Hash	SHA-384
HSM	FIPS 140-3 Level 2 z PQC

Status PQC: hybrydowy obowiązkowy od 2026.

TIER STATE (2500 €+/użytkownik/miesiąc):

Warstwa	Profil od 2026
IKEv2 Key Exchange	P-384 + ML-KEM-1024 (hybrydowy, obowiązkowy)
TLS 1.3 Key Exchange	P384_MLKEM1024 (obowiązkowy)
Podpisy certyfikatów	ECDSA P-384 + ML-DSA-87 (dual-signature, przejście na pełny PQC do 2030)
Szyfr symetryczny	AES-256-GCM
Hash	SHA-384
HSM	FIPS 140-3 Level 3 z PQC (ML-KEM, ML-DSA)

TEE	AMD SEV-SNP lub Intel TDX z attestation PQC
-----	---

Status PQC: hybrydowy obowiązkowy od 2026, pełny PQC obowiązkowy od 2030.

Różnice między tierami odzwierciedlają nie tylko poziom bezpieczeństwa, ale także wymagania regulacyjne klientów. Tier STATE musi być zgodny z CNSA 2.0, co dyktuje wybór P-384 (nie Curve25519), ML-KEM-1024 (nie 768), ML-DSA-87 (nie 65) i SHA-384.

73.8 Profile dla regulated i sovereign — CNSA 2.0 alignment table

Status: [N] Normatywny Odbiorca: Compliance Officer, Architekt Bezpieczeństwa, Pre-sales (sektor publiczny) Wpływ na baseline: Krytyczny Powiązane rozdziały: 73.7, 72.6, 74.10

Klienci z sektora regulowanego (rządowego, obronnego, infrastruktury krytycznej) wymagają zgodności z konkretnymi standardami kryptograficznymi. CNSA 2.0 (NSA) jest najbardziej restrykcyjnym zestawem wymagań i stanowi punkt odniesienia dla tieru STATE.

Tabela zgodności CNSA 2.0 — algorytmy SYLION:

Funkcja	CNSA 2.0 — wymagany algorytm	SYLION STATE — implementacja	Status zgodności
Szyfrowanie symetryczne	AES-256	AES-256-GCM	✔️ Zgodny
Hash	SHA-384	SHA-384 (SHA-512 dla Root CA)	✔️ Zgodny
Key Establishment	ML-KEM-1024	P-384 + ML-KEM-1024 (hybrydowy) → ML-KEM-1024 (2030)	✔️ Zgodny (hybryd dozwolony w okresie przejściowym)
Podpis cyfrowy	ML-DSA-87	ECDSA P-384 + ML-DSA-87 → ML-DSA-87 (2030)	✔️ Zgodny
Podpis firmware/kodu	ML-DSA-87 lub LMS/XMSS	ML-DSA-87	✔️ Zgodny
Podpis certyfikatu Root CA	ML-DSA-87	ML-DSA-87 + SLH-DSA (opcja)	✔️ Zgodny
Wymiana kluczy IKEv2	RFC 9370 z ML-KEM-1024	RFC 9370 ADD_KE z ML-KEM-1024	✔️ Zgodny
TLS	TLS 1.3 z hybrydowym PQC	TLS 1.3 z P384_MLKEM1024	✔️ Zgodny

Harmonogram przejścia SYLION STATE na pełny CNSA 2.0:

Rok	Działanie	Status
2025	Hybrydowy transport PQC w testach	✔️ Zrealizowane
2026	Hybrydowy transport PQC w produkcji (IKEv2, TLS)	🔄 W trakcie
2027	Hybrydowa PKI (dual-signature certyfikaty), CNSA 2.0 compliance dla nowych wdrożeń	Planowane
2028	Pełna PKI PQC, ceremonia nowego Root CA z ML-DSA-87	Planowane
2030	Wyłączne użycie PQC (brak klasycznych algorytmów w nowych sesjach)	Planowane

Profile europejskie: Klienci podlegający regulacjom europejskim (eIDAS, ETSI, BSI) powinni stosować profile zgodne z rekomendacjami BSI (TR-02102-1) i ANSSI, które są zbieżne z CNSA 2.0. SYLION STATE z profilem CNSA 2.0 spełnia lub przekracza wymagania europejskie.

Sovereign deployment: Dla wdrożeń sovereign (dedykowana infrastruktura, wyizolowana sieciowo, w kraju klienta) profil kryptograficzny może być dostosowany do lokalnych wymagań regulacyjnych. SYLION udostępnia mechanizm konfiguracji polityki kryptograficznej per tenant, z walidacją zgodności z wybranym profilem regulacyjnym.

Rozdział 74. Migracja do PQC

74.1 Krypto-zwinność (Crypto-agility) — architecture that can swap algorithms

Status: [N] Normatywny Odbiorca: Architekt Bezpieczeństwa, Software Architect, DevOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 74.2, 74.3, 73.7

Krypto-zwinność (crypto-agility) to zdolność systemu do wymiany algorytmów kryptograficznych bez konieczności przebudowy architektury. W kontekście zagrożeń kwantowych i szybko zmieniającego się krajobrazu kryptograficznego, krypto-zwinność jest fundamentalnym wymaganiem architektonicznym SYLION.

Zasady krypto-zwinności SYLION:

Algorytmy jako parametry, nie stałe — żaden algorytm kryptograficzny nie może być zakodowany na stałe (hardcoded) w kodzie źródłowym. Wybór algorytmu musi być konfigurowalny przez politykę bezpieczeństwa i profil kryptograficzny tenanta.

Abstrakcja warstwy kryptograficznej — wszystkie operacje kryptograficzne (szyfrowanie, podpis, wymiana kluczy, hash) muszą przechodzić przez ujednolicony interfejs (Crypto Provider), który deleguje do konkretnej implementacji. Zmiana algorytmu wymaga jedynie aktualizacji konfiguracji providera, nie kodu aplikacji.

Negocjacja algorytmów — protokoły (IKEv2, TLS 1.3) natywnie wspierają negocjację algorytmów. SYLION musi utrzymywać listy dozwolonych algorytmów (allow-lists) per tier, aktualizowane centralnie.

Wersjonowane profile kryptograficzne — profile (np. „SYLION-STATE-2026-Q4”) definiują kompletny zestaw algorytmów dla danego tieru i okresu. Migracja polega na przejściu na nowy profil, z okresem kompatybilności wstecznej.

Audytowalność kryptografii — CBOM (Cryptographic Bill of Materials) dokumentuje wszystkie użyte algorytmy, biblioteki i ich wersje. Zmiana algorytmu generuje zdarzenie audytu.

Implementacja w SYLION:

strongSwan (IKEv2) — konfiguracja cipher suite w plikach polityki (/etc/strongswan.d/), nie w kodzie. Przejście na PQC wymaga: aktualizacji strongSwan do wersji z liboqs, dodania hybrydowych propozali, aktualizacji polityki.

OpenSSL/BoringSSL (TLS) — konfiguracja grup kluczy i cipher suites. Przejście na PQC wymaga: linkowania z oqs-provider, aktualizacji konfiguracji SSL context.

HSM (PKCS#11) — mechanizmy kryptograficzne definiowane przez tokeny PKCS#11. Przejście na PQC wymaga: aktualizacji firmware HSM, rejestracji nowych mechanizmów.

Matrix (Vodozemac/libolm) — szyfrowanie E2EE. Przejście na PQC wymaga aktualizacji bibliotek Olm do wersji z PQC key exchange.

Krypto-zwinność nie jest projektem jednorazowym, lecz trwałą właściwością architektury. SYLION musi walidować krypto-zwinność w testach regresji przy każdym wydaniu.

74.2 Inventory kryptografii — CBOM (Cryptographic Bill of Materials)

Status: [N] Normatywny Odbiorca: Architekt Bezpieczeństwa, Compliance Officer, Security Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 74.1, 74.3, 86.1

Cryptographic Bill of Materials (CBOM) jest kompletnym inwentarzem wszystkich algorytmów kryptograficznych, bibliotek, kluczy i certyfikatów używanych w systemie SYLION. CBOM stanowi punkt wyjścia dla planowania migracji PQC i jest wymagany przez CNSA 2.0 jako warunek wstępny przejścia.

Struktura CBOM SYLION:

Komponent	Biblioteka kryptograficzna	Algorytmy wymiany kluczy	Algorytmy podpisu	Szyfry symetryczne	Hash	Status PQC
strongSwan (IKEv2)	libstrongswan + liboqs	ECDH Curve25519/P-384 + ML-KEM	RSA/ECDSA (auth)	AES-256-GCM	SHA-384	Hybrydowy
Nginx/HAProxy (TLS)	OpenSSL 3.x + oqs-provider	X25519/P-384 + ML-KEM	ECDSA/ML-DSA (cert)	AES-256-GCM	SHA-384	Hybrydowy
Matrix (Synapse)	Python cryptography	X25519 (TLS)	Ed25519 (signing)	AES-256	SHA-256	Klasyczny
Vodozemac (E2EE)	Rust crypto	X25519 (Olm)	Ed25519 (Olm)	AES-256-CTR	SHA-256	Klasyczny
Firecracker (attestation)	OpenSSL	—	ECDSA (TEE attestation)	AES-256	SHA-384	Klasyczny
HSM (PKCS#11)	Firmware HSM	ECDH P-384 + ML-KEM-1024	ECDSA P-384 + ML-DSA-87	AES-256-KWP	SHA-384	Hybrydowy
CI/CD (signing)	cosign/sigstore	—	ECDSA P-256 → ML-DSA-65	—	SHA-256	Planowana migracja
CDR (file inspection)	libcrypto	—	—	AES-256-GCM (encrypted processing)	SHA-256	N/A

Procedura aktualizacji CBOM: 1. CBOM jest generowany automatycznie z konfiguracji i manifestów komponentów. 2. Aktualizacja CBOM następuje przy każdym release (CI/CD gate). 3. Audyt CBOM — kwartalnie przez Security Engineer, rocznie przez audytora zewnętrznego. 4. Odchylenia od docelowego profilu kryptograficznego są raportowane jako niezgodność i eskalowane.

CBOM jako narzędzie migracji: CBOM umożliwia identyfikację komponentów wymagających migracji PQC, priorytetyzację (najpierw transport, potem PKI, na końcu aplikacje) i śledzenie postępu. Każdy wpis CBOM ma przypisany status migracji: „Klasyczny”, „Hybrydowy”, „Pełny PQC”, „N/A”.

74.3 Phased rollout — Phase 1: hybrid transport (2026), Phase 2: hybrid PKI (2027), Phase 3: full PQC (2028–2030)

Status: [N] Normatywny Odbiorca: CISO, Program Manager, Architekt Bezpieczeństwa Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.6, 73.7, 74.4–74.10

Migracja do kryptografii postkwantowej w SYLION jest realizowana w trzech fazach, z zachowaniem kompatybilności wstecznej i możliwości wycofania na każdym etapie.

FAZA 1: Hybrydowy transport (2025 Q4 – 2026 Q4)

Cel: ochrona nowych sesji komunikacyjnych przed atakiem HNDL poprzez hybrydowe wymiany kluczy w IKEv2 i TLS.

Zakres: - IKEv2: konfiguracja strongSwan z hybrydowymi propozalami (ECDH + ML-KEM via RFC 9370). - TLS 1.3: aktualizacja OpenSSL/oqs-provider, konfiguracja hybrydowych grup kluczy. - Test wydajności: walidacja narzutu <20 ms na handshake. - Rollout: canary (5% ruchu STATE) → rolling (50%) → full. - Rollback: usunięcie hybrydowych propozali z polityki, powrót do klasycznego profilu.

Priorytet: STATE → PRO → STANDARD.

FAZA 2: Hybrydowa PKI (2027 Q1 – 2028 Q2)

Cel: ochrona integralności certyfikatów i podpisów przez hybrydowe certyfikaty (dual-signature).

Zakres: - Emisja nowego Intermediate CA z kluczem hybrydowym (ECDSA P-384 + ML-DSA-87). - Generowanie certyfikatów serwerowych i klienckich z podwójnym podpisem. - Aktualizacja chain validation w strongSwan, OpenSSL i aplikacjach. - Migracja code signing do ML-DSA. - Ceremonia klucza PQC Root CA (SLH-DSA lub ML-DSA-87).

FAZA 3: Pełna PQC (2028 Q3 – 2030 Q4)

Cel: wyłączenie klasycznych algorytmów asymetrycznych z nowych sesji i certyfikatów.

Zakres: - IKEv2: wyłączne propozale ML-KEM-1024 (STATE) / ML-KEM-768 (PRO). - TLS 1.3: wyłączne grupy ML-KEM. - PKI: certyfikaty podpisywane wyłącznie ML-DSA (bez dual-signature). - Decommissioning klasycznych kluczy CA. - Audyt końcowy CBOM — potwierdzenie braku klasycznych algorytmów asymetrycznych w systemie.

Kamienie milowe i gatekeepers: Przejście między fazami wymaga: (a) pozytywnych wyników testów wydajnościowych i interoperacyjności, (b) podpisania decision record przez CISO, (c) aktualizacji CBOM, (d) komunikacji z klientami o zmianach.

74.4 Hybrydowe wymiany kluczy — IKEv2 z ADD_KEY (RFC 9370), TLS 1.3

Status: [N] Normatywny Odbiorca: Network Engineer, Security Engineer, Architekt Bezpieczeństwa Wpływ na baseline: Krytyczny Powiązane rozdziały: 73.1, 73.6, 74.5

RFC 9370 (Multiple Key Exchanges in IKEv2) definiuje framework dla hybrydowych wymian kluczy w IKEv2. SYLION implementuje ten framework z konkretną instancją: klasyczna wymiana ECDH + postkwantowa enkapsulacja ML-KEM.

Przebieg hybrydowego handshake IKEv2 w SYLION:

Initiator (terminal) Responder (G1/G2) || |--- IKE_SA_INIT (KE: ECDH P-384, || SA: ENCR_AES_GCM_16_256, || PRF_HMAC_SHA2_384, || ADDKE1: ML-KEM-1024) -----> || |<--- IKE_SA_INIT Response || (KE: ECDH P-384 response, || SA accepted) -----| || |--- IKE_INTERMEDIATE #1 || (KE: ML-KEM-1024 || ciphertext) -----> || |<--- IKE_INTERMEDIATE #1 Response || (KE: ML-KEM-1024 || encapsulated key) -----| || | SKEYSEED = PRF(Ni | Nr, || ECDH_shared || MLKEM_shared) || |--- IKE_AUTH (AUTH: ML-DSA-87 || signature) -----> || |<--- IKE_AUTH Response -----|

Kluczowe aspekty implementacji:

- Negocjacja — Transform Type 4 (klasyczna DH) w IKE_SA_INIT, Additional Key Exchange Transform Types (ADDKE1) dla ML-KEM. Obie strony muszą wspierać te same algorytmy.
- Fragmentacja — payload ML-KEM-1024 (klucz publiczny: 1568 B, szyfrogram: 1568 B) może przekraczać typowy MTU. IKE_INTERMEDIATE wspiera fragmentację IKEv2 (RFC 7383), co rozwiązuje problem.
- Derivation — shared secret z ML-KEM jest konkatelowany z shared secret z ECDH przed wejściem do PRF. To zapewnia, że bezpieczeństwo wynikowego klucza jest co najmniej tak silne jak silniejszy z dwóch mechanizmów.
- Rekey — przy rekeying tunelu IPsec (CREATE_CHILD_SA lub IKE_FOLLOWUP_KEY per RFC 9370) wykonywana jest ponowna hybrydowa wymiana kluczy.

TLS 1.3 Hybrid Key Exchange:

- TLS 1.3 implementuje hybrydowe wymiany kluczy przez rozszerzenie supported_groups o grupy hybrydowe. Klient wysyła KeyShare z połączonym kluczem publicznym (X25519 key || ML-KEM-768 public key), serwer odpowiada połączonym szyfrogramem. Shared secret = HKDF(X25519_shared || ML-KEM_shared).
- Implementacja w SYLION opiera się na OpenSSL 3.x z oqs-provider, który rejestruje hybrydowe grupy kluczy (np. x25519_mlkem768, p384_mlkem1024) jako named groups.

74.5 Migracja transportu — strongSwan PQC support, liboqs integration

- Status: [N] Normatywny Odbiorca: Network Engineer, DevOps, Security Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 74.4, 73.1, 79.1
- Migracja warstwy transportowej IPsec do hybrydowego PQC wymaga aktualizacji strongSwan, integracji z biblioteką liboqs oraz konfiguracji hybrydowych propozali IKEv2.
- Wymagania softwareowe:

Komponent	Minimalna wersja	Funkcja PQC
strongSwan	6.0+	Wsparcie RFC 9370 (ADD_KEY), plugin oqs
liboqs	0.10+	Implementacja ML-KEM-768, ML-KEM-1024
oqs-provider (OpenSSL)	0.6+	Hybrydowe grupy TLS 1.3
OpenSSL	3.2+	Wsparcie oqs-provider

- Konfiguracja strongSwan z hybrydowym PQC (STATE):
`connections { sylion-state { version = 2 proposals = aes256gcm16-sha384-prfsha384-ecp384-ke1_mlkem1024 local { auth = pubkey certs = sylion-gw.crt } remote { auth = pubkey } children { net { esp_proposals = aes256gcm16-sha384 } } }`
- Procedura migracji (per bramka G1/G2):
 - Przygotowanie — aktualizacja strongSwan do wersji 6.0+, instalacja liboqs, kompilacja pluginu oqs dla strongSwan. Walidacja w środowisku staging.
 - Konfiguracja dual-proposal — dodanie hybrydowego propozala obok klasycznego. strongSwan negocjuje najsilniejszy wspólny zestaw. Terminale z PQC używają hybrydowego handshake, starsze terminale wracają do klasycznego.
 - Canary deployment — aktywacja na 5% bramek STATE, monitorowanie latencji handshake, success rate, error logs.
 - Rolling deployment — stopniowe rozszerzanie na kolejne bramki. Sesja drain przed aktualizacją, HA zachowany.
 - Wymuszenie PQC — po walidacji (min. 30 dni w produkcji bez regresji), usunięcie klasycznych propozali z konfiguracji bramek STATE. Terminale bez PQC tracą możliwość połączenia (wymagana aktualizacja firmware).
 - Walidacja — test penetracyjny: próba ustanowienia tunelu bez ML-KEM (musi być odrzucona), weryfikacja logów IKEv2 (potwierdzenie użycia ADD_KEY).
 - Procedura rollback: W przypadku problemów: przywrócenie konfiguracji z dual-proposal (hybrydowy + klasyczny) lub pełnego klasycznego profilu. Rollback nie wymaga restartu strongSwan — wystarczy przeładowanie konfiguracji (swanctl -load-all).

74.6 Migracja PKI — hybrid certificates, CA key ceremony for PQC root CA

- Status: [N] Normatywny Odbiorca: PKI Administrator, Architekt Bezpieczeństwa, CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.3, 73.2, 73.3, 75.5
- Migracja PKI do algorytmów postkwantowych jest bardziej złożona niż migracja transportu, ponieważ wymaga zmiany łańcucha zaufania, ceremonii kluczy w HSM i zachowania kompatybilności w okresie przejściowym.
- Strategia: podwójne certyfikaty (dual-signature) w okresie przejściowym
- W okresie przejściowym (2027–2030) SYLION emituje certyfikaty z podwójnym podpisem — klasycznym (ECDSA) i postkwantowym (ML-DSA). Klienci wspierający PQC weryfikują podpis ML-DSA, starsi klienci weryfikują podpis ECDSA. Oba podpisy są umieszczone w certyfikacie X.509 (rozszerzenie AltSignatureAlgorithm, AltSignatureValue per draft-ounsworth-pq-composite-sigs).
- Hierarchia PKI w okresie przejściowym:

Root CA (klasyczny — ECDSA P-384, istniejący) | — Intermediate CA (hybrydowy — ECDSA P-384 + ML-DSA-87) | — Server cert (hybrydowy) | — Client cert (hybrydowy) | Root CA (PQC — ML-DSA-87, nowy, 2028) | — Intermediate CA (PQC — ML-DSA-87) | — Server cert (ML-DSA-87) | — Client cert (ML-DSA-87)

Ceremonia klucza PQC Root CA:

Ceremonia musi być przeprowadzona w środowisku air-gapped z HSM certyfikowanym FIPS 140-3 Level 3 wspierającym ML-DSA-87.

Procedura: 1. Przygotowanie HSM — weryfikacja firmware, audyt fizyczny, inicjalizacja partycji PQC. 2. Generowanie klucza Root CA — ML-DSA-87 (lub SLH-DSA jako alternatywa), w HSM, w obecności minimum 3 Key Custodians. 3. Self-signed Root Certificate — generacja certyfikatu X.509 v3 z podpisem ML-DSA-87, Subject: „SYLION PQC Root CA”, ważność: 20 lat. 4. Dystrybucja zaufania — certyfikat Root CA PQC dystrybuowany do trust store terminali, bramek G1/G2, serwerów Matrix i komponentów zarządzania. 5. Cross-certification — opcjonalnie: klasyczny Root CA podpisuje certyfikat PQC Root CA (i odwrotnie), tworząc most zaufania między starą a nową hierarchią. 6. Dokumentacja — protokół ceremonii, nagranie video (opcjonalnie), podpisy Key Custodians, hash certyfikatu opublikowany w transparency log.

Harmonogram migracji PKI:

Etap	Termin	Działanie
1	2027 Q1	Emisja hybrydowego Intermediate CA
2	2027 Q2–Q4	Rolowanie hybrydowych certyfikatów serwerowych i klienckich
3	2028 Q1	Ceremonia PQC Root CA
4	2028 Q2–2029	Emisja pełnych PQC certyfikatów pod nowym Root CA
5	2030	Wycofanie klasycznego Root CA dla nowych certyfikatów

74.7 Migracja aplikacji i TLS — application-level TLS updates

Status: [N] Normatywny Odbiorca: Software Engineer, DevOps, Architekt Bezpieczeństwa Wpływ na baseline: Wysoki Powiązane rozdziały: 74.5, 74.6, 73.6

Migracja TLS na poziomie aplikacji obejmuje wszystkie komponenty SYLION komunikujące się za pomocą TLS 1.3: serwery Matrix (Synapse/Dendrite), API zarządzania, telemetria, SIEM, oraz komunikacja wewnętrzna między mikroservisami.

Wymagania bibliotek kryptograficznych:

Biblioteka	Wymagana wersja	Konfiguracja PQC
OpenSSL	3.2+	oqs-provider zainstalowany, grupy hybrydowe zarejestrowane
BoringSSL	Bieżąca (Google)	Wbudowane wsparcie PQC (X25519Kyber768)
rustls	0.23+	aws-lc-rs z ML-KEM
Python cryptography	43+	Backend OpenSSL z oqs-provider
Go crypto/tls	Go 1.23+	Eksperymentalne wsparcie ML-KEM

Procedura migracji per komponent:

Reverse proxy (Nginx/HAProxy) — konfiguracja ssl_ecdh_curve z hybrydowymi grupami, priorytet: x25519_mlkem768 (PRO) lub p384_mlkem1024 (STATE), fallback na klasyczny X25519/P-384. Test: openssl s_client z wymuszeniem grupy hybrydowej.

Matrix homeserver (Synapse) — Synapse korzysta z Python cryptography → OpenSSL backend. Wystarczy zaktualizować OpenSSL i zainstalować oqs-provider. Federation API wymaga koordynacji z innymi homeserverami — hybrydowe grupy muszą być w fallback, nie wymuszane.

API zarządzania — backend Go/Rust z TLS terminacją na reverse proxy lub natywną. Aktualizacja do wersji runtime z PQC, konfiguracja cipher suite.

Telemetria i SIEM — eksport logów/metryk do Zone 4 przez TLS. Aktualizacja klientów (Fluent Bit, OpenTelemetry Collector) do wersji z OpenSSL 3.x + oqs-provider.

Komunikacja wewnętrzna (mTLS) — mikroservisy w mesh sieciowym (Consul Connect, Envoy) z mTLS. Aktualizacja Envoy/sidecar do wersji z PQC, aktualizacja certyfikatów klienckich do hybrydowych.

Testowanie: Każdy komponent po migracji przechodzi: - Test połączenia z wymuszeniem grupy hybrydowej. - Test połączenia z wymuszeniem grupy klasycznej (fallback). - Test wydajności (throughput, latencja). - Test interoperacyjności z komponentami niemigrowanymi (graceful degradation).

74.8 Migracja integracji — partner API TLS, SIEM export, external IdP

Status: [R] Rekomendowany Odbiorca: Integration Engineer, Architekt Bezpieczeństwa, DevOps Wpływ na baseline: Średni Powiązane rozdziały: 74.7, 88.7

Migracja integracji zewnętrznych do PQC jest ograniczona przez gotowość partnerów i dostawców. SYLION nie może wymusić PQC na systemach zewnętrznych, ale musi zapewnić kompatybilność i ścieżkę migracji.

Kategorie integracji i ich gotowość PQC:

Integracja	Protokół	Status PQC partnera	Strategia SYLION
SIEM (Splunk, Elastic)	TLS 1.3 (syslog-TLS, HTTPS)	Brak wsparcia PQC w 2026	Klasyczny TLS z planem migracji
External IdP (Azure AD, Okta)	OIDC/SAML over TLS	Azure AD: eksperymentalny PQC, Okta: brak	Hybrydowy TLS gdy dostępny
Partner API	REST/gRPC over TLS	Zróźnicowany	Dual-mode: PQC gdy partner wspiera, klasyczny jako fallback
Email gateway	SMTP/TLS	Brak PQC	Klasyczny TLS
Backup storage (S3-compatible)	HTTPS	AWS: eksperymentalny PQC TLS	Hybrydowy gdy dostępny

Zasady migracji integracji:

Best-effort PQC — SYLION oferuje hybrydowe TLS dla wszystkich integracji. Jeśli partner nie wspiera PQC, negocjacja degraduje do klasycznego profilu automatycznie.

Izolacja wrażliwości — integracje z partnerami bez PQC nie powinny przysyłać danych najwyższej wrażliwości. Jeśli SIEM export wymaga ochrony PQC, a SIEM nie wspiera PQC, rozważenie on-premise SIEM z PQC-capable TLS lub szyfrowanie danych przed eksportem (application-layer encryption z ML-KEM).

Monitorowanie gotowości — kwartalny przegląd statusu PQC u kluczowych partnerów integracyjnych. Aktualizacja CBOM o status integracji.

Wymagania kontraktowe — dla nowych integracji (od 2027): wymóg wsparcia TLS 1.3 z hybrydowymi grupami kluczy w SLA/kontrakcie.

Dokumentacja — dla każdej integracji: udokumentowanie profilu kryptograficznego, statusu PQC, ryzyka i planu migracji.

Migracja integracji jest procesem ciągłym, uzależnionym od ekosystemu. SYLION musi być gotowy do aktywacji PQC natychmiast po uzyskaniu wsparcia po stronie partnera.

74.9 Testing and rollback — performance benchmarks, interoperability testing

Status: [N] Normatywny Odbiorca: QA Engineer, Network Engineer, Security Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 74.5, 78.1–78.7, 81.1

Każdy etap migracji PQC musi być walidowany zestawem testów wydajnościowych, interoperacyjności i bezpieczeństwa przed wdrożeniem produkcyjnym. Plan rollback musi być przetestowany z taką samą rygorystycznością jak sam deployment.

Benchmarki wydajnościowe:

Metryka	Wartość bazowa (klasyczny)	Dopuszczalny narzut PQC	Metoda pomiaru
IKEv2 handshake latency	~50 ms	+ 15–20 ms (hybrydowy ML-KEM-768/1024)	ike-bench na 1000 handshake’ów
TLS 1.3 handshake latency	~25 ms	+ 10–15 ms (hybrydowa grupa)	openssl s_time
IPsec ESP throughput	Baseline (AES-256-GCM)	0% degradacji (AES nie zmieniony)	iperf3 przez tunel
Certificate verification	<1 ms (ECDSA)	+ 2–5 ms (ML-DSA-65/87)	Microbenchmark
HSM signing throughput	~5000 ops/s (ECDSA P-384)	~500–1000 ops/s (ML-DSA-87)	HSM benchmark tool

Testy interoperacyjności:

Cross-vendor IKEv2 — SYLION strongSwan ↔ Cisco IOS-XE (PQC), Palo Alto PAN-OS (PQC), Fortinet FortiGate (PQC). Weryfikacja negocjacji hybrydowej, fallback do klasycznej.

Cross-library TLS — SYLION OpenSSL+oqs ↔ BoringSSL (Chrome), rustls (Rust clients), Go crypto/tls. Weryfikacja hybrydowych grup kluczy.

PKI chain validation — hybrydowe certyfikaty weryfikowane przez OpenSSL, NSS (Firefox), BoringSSL (Chrome), Java keytool.

HSM interoperability — operacje ML-KEM/ML-DSA na HSM Utimaco, Thales Luna, Entrust nShield — weryfikacja PKCS#11 mechanizmów.

Plan rollback:

Każda faza migracji ma zdefiniowany rollback: - Transport (IKEv2): przeładowanie konfiguracji strongSwan z klasycznym profilem (swanctl –load-all). Czas: <5 minut. Istniejące tunele kontynuują z bieżącym kluczem, nowe tunele negocjują klasyczny profil. - Transport (TLS): aktualizacja konfiguracji reverse proxy, przeładowanie (nginx -s reload). Czas: <2 minuty. - PKI: powrót do certyfikatów klasycznych z osobnej hierarchii CA. Czas: minuta na wymianę certyfikatu, ale wymaga dystrybucji. - Full rollback: w najgorszym scenariuszu, pełne cofnięcie do klasycznego profilu zajmuje <30 minut z automatyzacją Ansible/Terraform.

Każdy plan rollback jest testowany w środowisku staging przed każdą fazą migracji.

74.10 Roadmapa CNSA 2.0 — official US government schedule, SYLION alignment

Status: [N] Normatywny Odbiorca: CISO, Compliance Officer, Product Owner Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.6, 73.8, 74.3

CNSA 2.0 (Commercial National Security Algorithm Suite 2.0), opublikowana przez NSA we wrześniu 2022 i zaktualizowana w 2024, definiuje harmonogram przejścia systemów NSS (National Security Systems) na algorytmy postkwantowe. Dla SYLION STATE, który obsługuje klientów rządowych i podmioty DIB (Defense Industrial Base), zgodność z CNSA 2.0 jest wymaganiem biznesowym i regulacyjnym.

Harmonogram CNSA 2.0:

Data	Typ systemu	Wymaganie	SYLION STATE — status
2025	Podpisy oprogramowania/firmware	Preferowane CNSA 2.0	✅ ML-DSA-87 code signing wdrożony
2026	Sprzęt sieciowy (VPN, routery)	Preferowane CNSA 2.0	🔄 Hybrydowy IKEv2 w rollout
1 sty 2027	Nowe akwizycje NSS	CNSA 2.0 obowiązkowe	Planowane — pełna zgodność
21 wrz 2026	FIPS 140-2	Certyfikaty FIPS 140-2 → Historical	✅ HSM z FIPS 140-3
31 gru 2030	Sprzęt sieciowy	CNSA 2.0 wyłącznie	Planowane — pełny PQC
31 gru 2031	Wszystkie NSS	Pełne wymuszenie CNSA 2.0	Planowane
2033	Aplikacje custom, legacy	CNSA 2.0 wyłącznie	Planowane
2035	NIST	Zakaz kryptografii podatnej na atak kwantowy	—

Algorytmy CNSA 2.0:

Funkcja	Algorytm CNSA 2.0	SYLION STATE
---------	-------------------	--------------

Szyfrowanie	AES-256	AES-256-GCM
Hash	SHA-384	SHA-384
Key Establishment	ML-KEM-1024	P-384 + ML-KEM-1024 → ML-KEM-1024
Digital Signature	ML-DSA-87	ECDSA P-384 + ML-DSA-87 → ML-DSA-87
Firmware Signing	ML-DSA-87 lub LMS/XMSS	ML-DSA-87

Luki i ryzyka:

FIPS 140-3 walidacja z PQC — proces walidacji FIPS 140-3 trwa średnio ponad 500 dni. HSM z PQC mogą nie mieć walidacji FIPS 140-3 z algorytmami PQC do 2027. SYLION musi monitorować status walidacji dostawców HSM.

FN-DSA (Falcon/FIPS 206) — NIST planuje finalizację FIPS 206 w 2026/2027. CNSA 2.0 może zostać zaktualizowana o FN-DSA. SYLION musi być gotowy na włączenie FN-DSA (krypto-zwinność).

Interoperacyjność — nie wszyscy partnerzy integracyjni będą gotowi na CNSA 2.0 w terminach NSA. SYLION musi utrzymywać tryb hybrydowy dla integracji zewnętrznych.

SYLION STATE jest na dobrej drodze do pełnej zgodności z CNSA 2.0 zgodnie z harmonogramem NSA. Kwartalny przegląd statusu migracji PQC z udziałem CISO i Product Ownera.

Rozdział 75. Integracja HSM z post-quantum

75.1 Wymagania dla HSM — FIPS 140-3 Level 3 for STATE

Status: [N] Normatywny Odbiorca: HSM Administrator, Architekt Bezpieczeństwa, Procurement Wpływ na baseline: Krytyczny Powiązane rozdziały: 72.5, 75.2, 75.6

HSM (Hardware Security Module) w architekturze SYLION stanowi korzeń zaufania kryptograficznego. Wymagania dla HSM muszą uwzględniać zarówno bieżące potrzeby operacyjne, jak i gotowość do migracji postkwantowej.

Wymagania bazowe per tier:

Wymaganie	STANDARD/PRO	STATE
Certyfikacja	FIPS 140-3 Level 2	FIPS 140-3 Level 3
Tamper resistance	Tamper-evident	Tamper-active (zeroizacja przy ingerencji fizycznej)
Algorytmy klasyczne	RSA-4096, ECDSA P-256/P-384, AES-256, SHA-384	RSA-4096, ECDSA P-384, AES-256, SHA-384/512
Algorytmy PQC	ML-KEM-768, ML-DSA-65 (wymagane od 2027)	ML-KEM-1024, ML-DSA-87 (wymagane od 2026)
Key generation	On-board TRNG (True Random Number Generator)	On-board TRNG z certyfikacją AIS 31 PTG.2
Backup/restore	Key backup z split custody	Key backup z M-of-N split custody, air-gapped
Performance	≥1000 ops/s (ECDSA P-256)	≥5000 ops/s (ECDSA P-384), ≥500 ops/s (ML-DSA-87)
Availability	Active-standby (HA pair)	Active-active cluster (min. 3 nodes)
Network interface	Ethernet, PKCS#11, KMIP	Ethernet, PKCS#11, KMIP, dedykowany VLAN
Auditing	Logs all operations	Tamper-evident audit log, exportowany do Zone 4

Wymagania specyficzne dla PQC:

Wsparcie algorytmów NIST PQC — HSM musi wspierać ML-KEM-768/1024 (FIPS 203) i ML-DSA-65/87 (FIPS 204) natywnie (w firmware), nie jedynie przez oprogramowanie klienckie. Kluczowa różnica: jeśli HSM wspiera PQC tylko przez SDK/API z generacją klucza w software, klucz PQC nigdy nie opuszcza oprogramowania i nie jest chroniony sprzętowo.

Key wrapping z ML-KEM — HSM musi obsługiwać opakowywanie kluczy symetrycznych mechanizmem ML-KEM (enkapsulacja, dekapulsacja) dla bezpiecznego eksportu/importu kluczy między HSM.

Signing z ML-DSA — HSM musi obsługiwać podpis i weryfikację ML-DSA natywnie. Wydajność podpisu ML-DSA-87: minimum 500 ops/s.

Firmware update path — HSM musi mieć udokumentowaną ścieżkę aktualizacji firmware do wersji z PQC, bez konieczności wymiany sprzętu. Jeśli wymiana sprzętu jest konieczna, musi to być uwzględnione w planowaniu budżetowym i harmonogramie.

Zgodność z CNSA 2.0 — dla tieru STATE, HSM musi być na liście zatwierdzonych produktów NSA (lub równoważnej liście krajowej).

75.2 Wsparcie PQC — which HSMs support ML-KEM/ML-DSA today

Status: [R] Rekomendowany Odbiorca: Procurement, Architekt Bezpieczeństwa, HSM Administrator Wpływ na baseline: Wysoki Powiązane rozdziały: 75.1, 75.6

Rynek HSM z natywnym wsparciem algorytmów PQC rozwija się dynamicznie. Stan na 2026 r.:

Producenci z natywnym wsparciem PQC:

Producent	Model	ML-KEM	ML-DSA	SLH-DSA	FIPS 140-3 L3	Uwagi
Utimaco	CryptoServer Se Gen2	ML-KEM-512/768/1024	ML-DSA-44/65/87	Planowane Q3 2026	Tak	Firmware 5.x+, natywne PQC
Thales	Luna Network HSM 7	ML-KEM-768/1024	ML-DSA-65/87	Nie	Tak	Firmware 7.4+, PQC module
Entrust	nShield XC	ML-KEM-768 (częściowe)	ML-DSA-65 (częściowe)	Nie	Tak	PQC via CodeSafe, nie natywne
Securiosys	Primus X	ML-KEM-1024	ML-DSA-87	Nie	W procesie	Natywne PQC, silna pozycja w UE

AWS	CloudHSM	Via SDK (nie natywne)	Via SDK	Nie	Tak (Level 3)	PQC operacje w software klienckim
Azure	Managed HSM	Planowane	Planowane	Nie	Tak (Level 3)	Roadmap 2027

Rekomendacje SYLION:

Tier STATE — Utimaco CryptoServer Se Gen2 lub Thales Luna 7 jako preferowane HSM. Oba oferują natywne wsparcie ML-KEM-1024 i ML-DSA-87 z certyfikacją FIPS 140-3 Level 3.

Tier PRO — Utimaco lub Thales, alternatywnie Securosys Primus X. FIPS 140-3 Level 2 wystarczający.

Tier STANDARD — CloudHSM z PQC via SDK akceptowalny (klucze PQC w software, klucze klasyczne w HSM). Migracja do natywnego PQC HSM gdy dostępny w ofercie chmury.

Monitoring roadmapy HSM: SYLION utrzymuje rejestr dostawców HSM z ich roadmapą PQC, aktualizowany kwartalnie. Decyzja o wyborze HSM dla nowych wdrożeń STATE uwzględnia: natywne wsparcie PQC, status certyfikacji FIPS 140-3, wydajność PQC, wsparcie producenta, cenę.

Ograniczenie: FIPS 140-3 z PQC: Na dzień 2026 r. żaden HSM nie posiada walidacji FIPS 140-3 obejmującej algorytmy PQC (ML-KEM, ML-DSA). Walidacja jest w toku u głównych producentów. SYLION akceptuje HSM z FIPS 140-3 Level 3 (dla algorytmów klasycznych) + wsparcie PQC w firmware (bez dedykowanej walidacji PQC) jako rozwiązanie przejściowe.

75.3 Opakowywanie kluczy (Key Wrapping) — ML-KEM for key encapsulation in HSM

Status: [N] Normatywny Odbiorca: HSM Administrator, Architekt Bezpieczeństwa, Security Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 73.1, 75.1

Key wrapping to proces zabezpieczania kluczy kryptograficznych podczas transferu między HSM, między HSM a aplikacją lub podczas backupu. W erze postkwantowej mechanizm key wrapping musi być oparty na algorytmach odpornych na atak kwantowy.

Bieżący mechanizm key wrapping w SYLION: Klucz symetryczny (AES-256) jest opakowywany kluczem asymetrycznym (RSA-OAEP lub ECDH+KDF) podczas eksportu z HSM. Klucz asymetryczny jest podatny na atak kwantowy — przechwycony wrapped key może zostać odzyskany po złamaniu klucza wrapping.

Docelowy mechanizm: hybrydowe key wrapping z ML-KEM:

ML-KEM Key Encapsulation — HSM generuje parę kluczy ML-KEM-1024 (STATE) lub ML-KEM-768 (PRO). Klucz publiczny jest eksportowany. Aplikacja (lub drugi HSM) enkapsuluje losowy klucz symetryczny (AES-256) przy pomocy klucza publicznego ML-KEM. Powstały szyfrogram jest przesyłany do HSM, który dekapsuluje klucz symetryczny.

Hybrydowe wrapping — w okresie przejściowym: $\text{wrapped_key} = \text{Encrypt}(\text{AES-256-KWP}, \text{key_material}, \text{derived_key})$, gdzie $\text{derived_key} = \text{KDF}(\text{ECDH_shared} \parallel \text{ML-KEM_shared})$. To zapewnia odporność na scenariusz, w którym jeden z mechanizmów jest kompromitowany.

Direct ML-KEM wrapping — po pełnej migracji PQC: $\text{wrapped_key} = \text{ML-KEM.Encaps}(\text{public_key}, \text{key_material})$. Brak komponentu klasycznego.

Procedura eksportu klucza z HSM (hybrydowa):

1. HSM generuje parę kluczy: $(\text{pk_ecdH}, \text{sk_ecdH}) + (\text{pk_mlkem}, \text{sk_mlkem})$ 2. Odbiorca otrzymuje pk_ecdH i pk_mlkem 3. Odbiorca: a. ECDH: $\text{shared_ecdH} = \text{ECDH}(\text{pk_ecdH}, \text{sk_odbiorca})$ b. ML-KEM: $(\text{ciphertext}, \text{shared_mlkem}) = \text{ML-KEM.Encaps}(\text{pk_mlkem})$ c. $\text{derived_key} = \text{HKDF-SHA-384}(\text{shared_ecdH} \parallel \text{shared_mlkem}, \text{salt}, \text{info})$ d. $\text{wrapped_key} = \text{AES-256-KWP}(\text{derived_key}, \text{key_to_export})$ 4. Odbiorca przesyła: $\text{ciphertext} + \text{wrapped_key}$ do HSM 5. HSM dekapsuluje, derivuje klucz, odpakuje

Ograniczenia: - Nie wszystkie HSM wspierają ML-KEM w kontekście PKCS#11 CKM_* mechanizmu key wrapping. Konieczne jest użycie custom mechanizmów lub obejść (generowanie shared secret przez ML-KEM, derivacja klucza, wrapping symetryczny). - Wydajność ML-KEM wrapping w HSM: ~200–500 ops/s (zależnie od modelu).

75.4 Attestation i signing — ML-DSA for code signing, audit log signing

Status: [N] Normatywny Odbiorca: Security Engineer, DevOps, Compliance Officer Wpływ na baseline: Wysoki Powiązane rozdziały: 73.2, 80.5

Podpisy cyfrowe generowane w HSM stanowią podstawę łańcucha zaufania SYLION — od podpisu kodu po integralność logów audytu. Migracja podpisów do ML-DSA zapewnia ich odporność na przyszłe ataki kwantowe.

Zastosowania podpisów HSM w SYLION:

Code signing (CI/CD):

Artefakty: kontenery Docker, obrazy Firecracker, firmware terminali, pakiety aktualizacji.

Bieżąco: ECDSA P-256 (cosign/sigstore).

Docelowo: ML-DSA-65 (PRO) / ML-DSA-87 (STATE).

Procedura: pipeline CI/CD wywołuje HSM API (PKCS#11) z haszem artefaktu, HSM zwraca podpis ML-DSA. Podpis jest dołączany do artefaktu i weryfikowany przed deployment.

Audit log signing:

Każdy wpis logu audytu w Zone 4 jest podpisywany kluczem HSM.

Bieżąco: ECDSA P-256, rotacja klucza co 1 rok.

Docelowo: ML-DSA-65 (PRO) / ML-DSA-87 (STATE).

Wydajność: przy ~100 wpisów/s, HSM musi obsługiwać ~100 ops/s podpisów ML-DSA. Utimaco/Thales: >500 ops/s — wystarczające.

TEE attestation signing:

Raporty attestation z AMD SEV-SNP / Intel TDX podpisywane kluczem platformy.

Kluczowe: weryfikacja attestation jest wykonywana przez management plane z użyciem klucza publicznego przechowywanego w HSM.

Docelowo: rozszerzenie łańcucha attestation o podpis ML-DSA.

Policy signing:

Polityki OPA/Rego podpisywane przed wdrożeniem.

ML-DSA zapewnia, że polityki nie mogą być sfałszowane retrospektywnie.

Dual-signing w okresie przejściowym: Wszystkie podpisy w okresie przejściowym (2027–2030) są generowane dwukrotnie: ECDSA (kompatybilność) + ML-DSA (odporność PQC). Oba podpisy są weryfikowane. Jeśli weryfikacja ECDSA nie jest wymagana przez odbiorcę, można ją pominąć po migracji.

Klucze podpisu w HSM: Klucze ML-DSA generowane i przechowywane w HSM, oznaczone jako non-exportable. Rotacja kluczy podpisu: co 1–2 lata dla code signing, co 1 rok dla audit log signing.

75.5 Key ceremonies under PQC — adapted ceremony procedures

Status: [N] Normatywny Odbiorca: PKI Administrator, CISO, HSM Administrator Wpływ na baseline: Krytyczny Powiązane rozdziały: 74.6, 75.1

Ceremonia kluczy PQC musi być dostosowana do specyfiki algorytmów postkwantowych — większe rozmiary kluczy, inne mechanizmy, nowe procedury weryfikacji. Procedura ceremonii musi być udokumentowana, audytowalna i powtarzalna.

Różnice między ceremonią klasyczną a PQC:

Element	Ceremonia klasyczna	Ceremonia PQC
Algorytm	ECDSA P-384	ML-DSA-87 (lub SLH-DSA)
Rozmiar klucza publicznego	97 B	2592 B (ML-DSA-87)
Rozmiar podpisu self-signed	96 B	4595 B (ML-DSA-87)
Czas generowania klucza	<100 ms	~200 ms
HSM firmware	Standardowy	Wymaga firmware z PQC
Weryfikacja cross-check	Eksport klucza publicznego, weryfikacja na drugim HSM	Jak klasyczna, ale z biblioteką PQC (liboqs)

Procedura ceremonii PQC Root CA:

Pre-ceremony (T-7 dni):

Weryfikacja HSM: firmware z ML-DSA-87, partycja PQC zainicjalizowana.

Weryfikacja skryptów ceremonii (zaktualizowane dla PQC).

Notyfikacja Key Custodians (minimum 3 z 5 wymaganych).

Przygotowanie środowiska air-gapped.

Ceremony Day:

Otwarcie protokołu ceremonii (video recording opcjonalnie).

Weryfikacja tożsamości Key Custodians (2× ID check).

Inicjalizacja HSM w trybie FIPS (jeśli reset).

Generowanie pary kluczy ML-DSA-87 w HSM (CKM_ML_DSA_87_KEY_PAIR_GEN).

Weryfikacja klucza: podpis testowej wiadomości, weryfikacja na niezależnym systemie z liboqs.

Generowanie self-signed Root CA certificate (X.509 v3, OID: id-ml-dsa-87).

Export certyfikatu (DER format), obliczenie hash SHA-384.

Publikacja hash w transparency log.

Backup klucza: M-of-N key split, każdy fragment na osobnym nośniku, dystrybuowany do Key Custodians.

Zamknięcie protokołu ceremonii.

Post-ceremony:

Dystrybucja certyfikatu Root CA PQC do trust stores.

Cross-certification z klasycznym Root CA (opcjonalnie).

Archiwizacja dokumentacji ceremonii.

Audyt niezależny (w ciągu 30 dni).

Ceremonia PQC Root CA jest zdarzeniem jednorazowym z wieloletnimi konsekwencjami. Musi być przeprowadzona z najwyższą starannością.

75.6 Ograniczenia HSM today — not all HSMs support PQC

Status: [R] Rekomendowany Odbiorca: Procurement, Architekt Bezpieczeństwa, CISO Wpływ na baseline: Wysoki Powiązane rozdziały: 75.1, 75.2

Migracja PQC w warstwie HSM napotyka na realne ograniczenia techniczne i rynkowe, które SYLION musi uwzględnić w planowaniu.

Ograniczenie 1: Brak natywnego wsparcia PQC w wielu HSM Znaczna część HSM w użyciu (i dostępnych na rynku) nie wspiera algorytmów PQC natywnie. CloudHSM (AWS), Azure Managed HSM, starsze modele Thales Luna i Entrust nShield wymagają aktualizacji firmware lub wymiany sprzętu.

Mitygacja: inwentaryzacja HSM we wszystkich wdrożeniach SYLION, ocena ścieżki upgrade, planowanie wymiany sprzętu z 12-miesięcznym wyprzedzeniem.

Ograniczenie 2: Wydajność PQC w HSM Operacje ML-DSA-87 w HSM są 5–10× wolniejsze niż ECDSA P-384. Dla scenariuszy wymagających dużej przepustowości podpisów (np. audit log signing przy 100+ ops/s) konieczne jest: - Użycie HSM z dedykowanym PQC acceleratorem. - Batching operacji podpisu (podpisywanie bloków logów zamiast pojedynczych wpisów). - Rozdzielenie obciążenia na klaster HSM (active-active).

Ograniczenie 3: FIPS 140-3 z algorytmami PQC Na dzień 2026 r. żaden HSM nie posiada walidacji FIPS 140-3, która explicite obejmuje algorytmy ML-KEM i ML-DSA. Walidacje są w procesie (Utimaco, Thales — przewidywane H2 2026 / H1 2027). W okresie przejściowym SYLION akceptuje „FIPS 140-3 Level 3 + PQC firmware” jako rozwiązanie tymczasowe.

Ograniczenie 4: PKCS#11 dla PQC Standard PKCS#11 nie definiuje jeszcze oficjalnie mechanizmów CKM_* dla ML-KEM i ML-DSA. Producenci HSM implementują własne rozszerzenia (vendor-specific CKM IDs). OASIS PKCS#11 Technical Committee pracuje nad aktualizacją (przewidywana 2026/2027). Do tego czasu SYLION musi obsługiwać vendor-specific mechanizmy.

Ograniczenie 5: Koszt HSM z natywnym PQC (Utimaco Se Gen2, Thales Luna 7 z PQC module) kosztuje 30–50% więcej niż model bez PQC. Dla wdrożeń STATE (min. 50 użytkowników, HA cluster) koszt HSM może wynosić 50.000–100.000 €.

Plan fallback: Jeśli HSM z natywnym PQC nie jest dostępny lub nie ma walidacji FIPS 140-3 z PQC: 1. Klucze klasyczne (Root CA, Intermediate CA) pozostają w HSM — chronione sprzętowo. 2. Klucze PQC generowane w software (liboqs) z zabezpieczeniem w TEE (AMD SEV-SNP/Intel TDX) — rozwiązanie przejściowe. 3. Migracja kluczy PQC do HSM natychmiast po uzyskaniu dostępu do HSM z walidacją PQC.

Rozdział 76. QKD, kanały kwantowe i elementy eksperymentalne [E]

76.1 Czym jest QKD — physics-based key distribution

Status: [E] Eksperymentalny Odbiorca: Architekt Bezpieczeństwa, R&D, CISO Wpływ na baseline: Niski Powiązane rozdziały: 76.2–76.7

Quantum Key Distribution (QKD) to metoda dystrybucji kluczy kryptograficznych oparta na zasadach fizyki kwantowej, a nie na założeniach o trudności obliczeniowej problemów matematycznych. W odróżnieniu od PQC, które bazuje na nowych algorytmach matematycznych, QKD wykorzystuje właściwości fotonów do wykrywania podsłuchu na fizycznym kanale transmisji.

Protokół BB84 (Bennett-Brassard 1984): Nadawca (Alice) przesyła fotony polaryzowane w jednej z dwóch baz (prostoliniowej lub przekątnej), każdy foton kodujący jeden bit. Odbiorca (Bob) mierzy fotony w losowo wybranej bazie. Po transmisji Alice i Bob porównują (przez klasyczny kanał uwierzytelniony) użyte bazy i odrzucają bity, dla których bazy się nie zgadzały. Wynikowy klucz jest bezpieczny informacyjnie (information-theoretic security) — podsłuchiwaniec (Eve) musi zaburzyć stan kwantowy fotonów próbując je odczytać, co jest wykrywane przez analizę statystyczną błędów.

Warianty QKD: - BB84 — oryginalny, polaryzacja fotonów. - E91 — oparty na splątaniu kwantowym (entanglement). - CV-QKD — continuous-variable QKD, bardziej kompatybilny z istniejącą infrastrukturą telekomunikacyjną. - MDI-QKD — measurement-device-independent, eliminuje słabości detektorów.

Dlaczego QKD jest interesujące: QKD oferuje bezpieczeństwo oparte na prawach fizyki, a nie na złożoności obliczeniowej. Nawet nieskończenie potężny komputer (klasyczny lub kwantowy) nie może złamać klucza dystrybuowanego QKD bez wykrycia. To fundamentalna różnica w porównaniu z PQC, gdzie bezpieczeństwo opiera się na założeniu, że określone problemy matematyczne (MLWE, hash functions) są trudne obliczeniowo.

Jednak, jak opisano w kolejnych podrozdziałach, QKD ma fundamentalne ograniczenia praktyczne, które czynią go nieprzydatnym jako baseline technologię SYLION.

76.2 Gdzie QKD miałoby sens — point-to-point fixed links

Status: [E] Eksperymentalny Odbiorca: R&D, Architekt Bezpieczeństwa Wpływ na baseline: Niski Powiązane rozdziały: 76.1, 76.6

Teoretyczne scenariusze zastosowania QKD w kontekście SYLION ograniczają się do wąskich, specyficznych przypadków użycia.

Scenariusz 1: Stałe łącza między centrami danych (datacenter interconnect) Dwa centra danych SYLION STATE w tej samej aglomeracji (dystans <50 km), połączone dedykowanym światłowodem dark fiber. QKD zapewnia dodatkową warstwę dystrybucji kluczy obok PQC — defence-in-depth.

Scenariusz 2: Sovereign datacenter links Wdrożenia sovereign (dedykowana infrastruktura w kraju klienta) z połączeniem między primary i DR datacenter. Klient rządowy może wymagać QKD jako dodatkowego zabezpieczenia.

Scenariusz 3: HSM-to-HSM key exchange Dystrybucja kluczy między HSM w różnych lokalizacjach — QKD eliminuje potrzebę transportu kluczy przez sieć opartą na algorytmach klasycznych lub PQC.

Realistyczna ocena: Wszystkie powyższe scenariusze wymagają: dedykowanego światłowodu, sprzętu QKD po obu stronach (~100.000 € per link), specjalistycznej obsługi, dystansu <100–150 km (bez repeaterów kwantowych, które nie istnieją komercyjnie). Żaden scenariusz nie jest częścią standardowej oferty SYLION — jedynie potencjalna opcja dla sovereign deployments z budżetem na eksperymentalne technologie.

76.3 Ograniczenia QKD — distance, cost, no internet routing

Status: [E] Eksperymentalny Odbiorca: R&D, CISO, Architekt Bezpieczeństwa Wpływ na baseline: Niski Powiązane rozdziały: 76.1, 76.4

QKD posiada fundamentalne ograniczenia, które uniemożliwiają jego użycie jako uniwersalnej technologii ochrony transportu.

Ograniczenie 1: Dystans Straty w światłowodzie ograniczają zasięg QKD do ~100–150 km bez repeaterów kwantowych. Repeaterzy kwantowe (quantum repeaters) wymagają pamięci kwantowej i korekty błędów kwantowych — technologie w fazie laboratoryjnej, nie komercyjnej. Sieci QKD oparte na zaufanych węzłach (trusted nodes) łamią model bezpieczeństwa — każdy węzeł pośredni ma dostęp do klucza.

Ograniczenie 2: Brak routingu internetowego QKD wymaga dedykowanego kanału optycznego (point-to-point) — nie może być routowane przez publiczny internet. SYLION łączy operatorów z bramkami G1/G2 przez internet publiczny. QKD jest fundamentalnie niekompatybilny z tym modelem.

Ograniczenie 3: Koszt Sprzęt QKD: ~100.000–500.000 € per link (nadajnik + odbiornik). Dedykowany dark fiber: ~1000–5000 €/km/rok. Utrzymanie: specjalistyczna obsługa, kalibracja optyczna.

Ograniczenie 4: Brak uwierzytelniania QKD wymaga uwierzytelnionego kanału klasycznego do porównania baz i korekty błędów. Uwierzytelnianie opiera się na klasycznej kryptografii (MAC, podpisy) — QKD nie eliminuje zależności od PQC/klasycznej kryptografii.

Ograniczenie 5: Przepustowość kluczy Typowe systemy QKD generują ~1–100 kbit/s klucza (zależnie od dystansu i technologii). Dla porównania, ML-KEM generuje 256-bitowy shared secret w ~40 μs. QKD nie może obsłużyć scenariuszy wymagających częstego rekeying lub wielu równoczesnych sesji.

Ograniczenie 6: Brak standaryzacji ETSI QKD ISG pracuje nad standardami, ale nie ma odpowiednika FIPS/NIST certyfikacji dla sprzętu QKD. Brak możliwości certyfikacji regulacyjnej.

76.4 Dlaczego QKD nie jest baseline SYLION

Status: [E] Eksperymentalny Odbiorca: CISO, Product Owner, R&D Wpływ na baseline: Niski Powiązane rozdziały: 76.1–76.3, 76.5

Na podstawie analizy ograniczeń QKD (76.3) formułujemy jednoznaczne stanowisko: QKD nie jest i nie będzie baseline komponentem SYLION w przewidywalnej przyszłości.

Argumenty:

PQC rozwiązuje ten sam problem — HNDL i podatność na komputer kwantowy są adresowane przez PQC (ML-KEM, ML-DSA) w warstwie software, bez wymagań sprzętowych, dystansowych czy kosztowych QKD.

Model operacyjny SYLION — operatorzy łączą się z bramkami G1/G2 przez internet publiczny, z dowolnej lokalizacji. QKD wymaga dedykowanego światłowodu point-to-point. Te modele są fundamentalnie niekompatybilne.

Koszty — QKD dodaje 100.000+ € per link bez mierzalnego wzrostu bezpieczeństwa w porównaniu z PQC dla scenariuszy SYLION.

Brak infrastruktury — nie istnieje globalna sieć kwantowa umożliwiająca routing kluczy QKD. Sieci testowe (np. EuroQCI) są w fazie pilotażowej i nie są dostępne komercyjnie.

Stanowisko NSA/CNSA 2.0 — NSA nie rekomenduje QKD jako elementu CNSA 2.0. NSA explicite stwierdza, że PQC jest wystarczające dla ochrony NSS i nie zaleca QKD jako alternatywy.

Stanowisko NIST — NIST nie certyfikuje QKD i nie planuje standardów analogicznych do FIPS 203/204/205 dla QKD.

Decyzja projektowa: QKD jest klasyfikowane jako [E] Eksperymentalne w architekturze SYLION. Nie jest uwzględniane w roadmapie produktowej, budżecie ani wymaganiach kwalifikacyjnych. Potencjalna przyszła integracja jest możliwa jedynie dla: - Sovereign deployments z explicite wymaganiem klienta. - Fixed datacenter links w ramach custom engagement. - Po osiągnięciu dojrzałości sieci kwantowych (nie przed 2030).

76.5 Relacja QKD do PQC — complementary not substitutes

Status: [E] Eksperymentalny Odbiorca: R&D, Architekt Bezpieczeństwa Wpływ na baseline: Niski Powiązane rozdziały: 76.1–76.4

QKD i PQC nie są zamienniki — adresują zagrożenie kwantowe z różnych perspektyw i oferują różne gwarancje bezpieczeństwa.

PQC (Post-Quantum Cryptography): - Bezpieczeństwo oparte na złożoności obliczeniowej (computational security). - Działa w software, przez internet, bez dedykowanego sprzętu. - Standardy NIST (FIPS 203/204/205), certyfikacja FIPS 140-3, zgodność CNSA 2.0. - Chroni wymianę kluczy i podpisy cyfrowe. - Potencjalnie podatne na przyszłe przełomowe ataki na problemy kratownicowe (choć żaden nie jest znany).

QKD (Quantum Key Distribution): - Bezpieczeństwo oparte na prawach fizyki (information-theoretic security). - Wymaga dedykowanego kanału optycznego, sprzętu, ograniczony dystans. - Brak standardów FIPS/NIST, brak certyfikacji regulacyjnej. - Chroni dystrybucję kluczy (nie podpisy cyfrowe). - Odporne nawet na przyszłe przełomowe algorytmy klasyczne i kwantowe.

Komplementarność: W scenariuszu maksymalnego bezpieczeństwa (sovereign, long-term classified data), połączenie PQC + QKD oferuje defence-in-depth: PQC chroni przed CRQC w warstwie software/sieciowej, QKD chroni dystrybucję kluczy na fizycznych łączach point-to-point. Jeśli PQC okaże się słabsze niż zakładano (przełomowy atak), QKD zapewni dodatkową warstwę. Jeśli QKD zawiedzie (problem sprzętowy, atak side-channel na detektor), PQC nadal chroni.

Jednak: w 2026 r. wartość dodana QKD nad PQC jest marginalna, a koszty i ograniczenia ogromne. SYLION rekomenduje PQC jako jedyną operacyjną warstwę ochrony postkwantowej, z QKD jako opcją eksperymentalną.

76.6 Scenariusze laboratoryjne — potential future integration

Status: [E] Eksperymentalny Odbiorca: R&D, Architekt Bezpieczeństwa Wpływ na baseline: Niski Powiązane rozdziały: 76.2, 76.5

SYLION rezerwuje ścieżkę architektoniczną dla potencjalnej przyszłej integracji QKD w scenariuszach laboratoryjnych i sovereign.

Scenariusz laboratoryjny 1: QKD + IPsec key injection QKD system generuje klucz współdzielony, który jest injektowany do strongSwan jako PSK (Pre-Shared Key) obok hybrydowej wymiany PQC. Triple protection: ECDH + ML-KEM + QKD-derived PSK.

Scenariusz laboratoryjny 2: QKD-backed HSM key exchange Dystrybucja klucza master między HSM w primary i DR datacenter odbywa się przez QKD link, eliminując transport klucza przez sieć.

Scenariusz laboratoryjny 3: Hybrid QKD/PQC gateway Dedykowana bramka łącząca dwa centra danych SYLION z QKD link + PQC IPsec overlay. Klucze QKD odświeżane co sekundę, injektowane do IKEv2 rekey.

Wymagania do realizacji: - Budżet R&D: min. 200.000 € (sprzęt QKD + dark fiber lease + labor). - Partner technologiczny: ID Quantique, Toshiba QKD, KEEQuant. - Timeline: nie wcześniej niż 2028. - Success criteria: demonstracja QKD key injection do strongSwan z utrzymaniem SLA produkcyjnego.

76.7 Rekomendacja projektowa — [E] experimental track only

Status: [E] Eksperymentalny Odbiorca: CTO, Architecture Board, R&D Wpływ na baseline: Niski Powiązane rozdziały: 76.1, 77.4, 74.3

QKD (Quantum Key Distribution) jest klasyfikowane jako [E] Eksperymentalne i nie wchodzi do roadmapy SYLION przed 2028 rokiem. Rekomendacja oparta na analizie dojrzałości technologii, kosztów i alternatyw.

Rekomendacja formalna: 1. QKD NIE jest elementem baseline SYLION — żaden tier (STANDARD, PRO, STATE) nie wymaga QKD. PQC (Post-Quantum Cryptography) rozwiązuje problem harvest-now-decrypt-later w sposób softwarowy, bez dedykowanej infrastruktury fizycznej. 2. QKD NIE jest w roadmapie — brak zaplanowanych prac implementacyjnych, brak alokacji budżetu, brak wymagań klientów. 3. QKD jest monitorowane — R&D team (0.05 FTE) śledzi postępy w: European Quantum Communication Infrastructure (EuroQCI), komercyjnych ofertach QKD (ID Quantique, Toshiba), standardach ETSI QKD.

Warunki re-evaluacji (2028 checkpoint): - Czy istnieje komercyjna sieć QKD w Europie z zasięgiem >500 km? - Czy koszt per link spadł poniżej 50K€? - Czy quantum repeaters osiągnęły commercial readiness? - Czy klient STATE tier zgłosił wymagania na QKD? - Czy regulacja (np. EU Cybersecurity Act amendment) wymaga QKD?

Jeśli ≥ 2 warunki spełnione → PoC (90 dni) w środowisku laboratoryjnym: fixed datacenter-to-datacenter link, pomiar key rate, latency, integration z istniejącym IKEv2 pipeline (QKD-generated keys jako PSK input).

Ryzyko braku QKD: Minimalne. PQC chroni przed quantum attacks na kryptografię asymetryczną. QKD chroni przed atakami na kryptografię per se (information-theoretic security), ale ten poziom ochrony nie jest wymagany dla SYLION use cases. Klienci wymagający information-theoretic security (np. ambasady, top-secret communication) powinni rozważyć dedykowane rozwiązania QKD poza SYLION.

Rozdział 77. Akceleratory kwantowe i elementy badawcze [E]

77.1 Potencjalne zastosowania obliczeń kwantowych w SYLION

Status: [E] Eksperymentalny Odbiorca: R&D, CTO, Architekt Bezpieczeństwa Wpływ na baseline: Niski Powiązane rozdziały: 76.1–76.7

Komputery kwantowe — oprócz zagrożeń dla kryptografii — mogą w przyszłości oferować korzyści obliczeniowe w obszarach potencjalnie istotnych dla platformy bezpiecznej komunikacji.

Scenariusz 1: Optymalizacja routingu sieciowego Algorytmy kwantowe (QAOA — Quantum Approximate Optimization Algorithm) mogą potencjalnie optymalizować routing ruchu między brankami G1/G2, datacenterami i regionami. Jednak obecne komputery kwantowe (NISQ — Noisy Intermediate-Scale Quantum) nie oferują przewagi nad klasycznymi solverami dla problemów o skali istotnej dla SYLION.

Scenariusz 2: Anomaly detection Quantum machine learning (QML) może przyspieszyć wykrywanie anomalii w teledziennym bezpieczeństwie (SOC). Jednak: QML jest w fazie wczesnych badań, nie istnieją produkcyjne systemy QML, a klasyczne metody ML (XGBoost, transformery) są w pełni adekwatne.

Scenariusz 3: Generowanie entropii Kwantowe generatory liczb losowych (QRNG) mogą dostarczać entropię o gwarantowanej losowości (quantum-certified randomness). To jedyne zastosowanie z potencjalną wartością operacyjną w perspektywie 3–5 lat. QRNG jest dostępne komercyjnie (ID Quantique Quantis, Quside) i może być zintegrowane z HSM jako źródło entropii.

Scenariusz 4: Symulacja kryptograficzna Symulacja zachowania algorytmów kryptograficznych (np. badanie odporności ML-KEM na ataki kwantowe) na komputerze kwantowym. Wartość akademicka, nie operacyjna.

77.2 Praktyczne ograniczenia — brak fault-tolerant quantum computers

Status: [E] Eksperymentalny Odbiorca: CTO, Architekt, R&D Wpływ na baseline: Niski Powiązane rozdziały: 77.1, 77.4, 76.3

Stan obecny technologii kwantowej nie pozwala na praktyczne zastosowania obliczeniowe w kontekście bezpieczeństwa ani optymalizacji infrastruktury SYLION.

Barier technologiczne: 1. Korekcja błędów — obecne komputery kwantowe (NISQ — Noisy Intermediate-Scale Quantum) mają wskaźnik błędów bramek rzędu 10^{-3} do 10^{-2} , podczas gdy fault-tolerant quantum computing wymaga $\sim 10^{-6}$. Overhead korekcji błędów: tysiące fizycznych qubitów na jeden qubit logiczny. 2. Skala — największe komputery kwantowe (2024–2026) mają 1000–1500 qubitów fizycznych. Złamanie RSA-2048 wymaga ~ 4000 qubitów logicznych, co przekłada się na miliony qubitów fizycznych z obecnymi schematami korekcji. 3. Decoherence — czas koherencji qubitów (mikro-do-milisekundy) ogranicza głębokość obwodów kwantowych. Praktyczne algorytmy wymagają milionów operacji. 4. Temperatura — większość platform (superprzewodnikowe, np. IBM, Google) wymaga chłodzenia do ~ 15 mK. Infrastruktura kriogeniczna kosztuje miliony EUR i wymaga specjalistycznej obsługi.

Implikacje dla SYLION: - Brak komercyjnie dostępnego komputera kwantowego zdolnego do złamania obecnej kryptografii w horyzoncie 2026–2030. - Quantum computing jako usługa (IBM Quantum, AWS Braket) oferuje dostęp do NISQ maszyn, ale ich możliwości nie wykraczają poza demonstracje i badania. - Żaden dostawca nie oferuje gwarancji SLA ani certyfikacji bezpieczeństwa dla obliczeń kwantowych. - Integracja z SYLION wymagałaby dedykowanej warstwy API, zarządzania kolejkami (quantum jobs), obsługi błędów specyficznych dla quantum, i fallbacku na klasyczne obliczenia.

Wniosek: Komputery kwantowe nie stanowią praktycznego narzędzia dla infrastruktury SYLION w przewidywalnym horyzoncie. Jedynym uzasadnionym działaniem jest monitorowanie postępów i przygotowanie architektonicznego punktu integracji (API gateway) na przyszłość — bez inwestycji w implementację.

77.3 Business vs marketing value

Status: [E] Eksperymentalny Odbiorca: CTO, Product Management, Marketing Wpływ na baseline: Niski Powiązane rozdziały: 77.1, 77.2, 77.4

Odróżnienie rzeczywistej wartości biznesowej od wartości marketingowej jest kluczowe przy podejmowaniu decyzji o inwestycjach w technologie kwantowe.

Wartość marketingowa (realna, ale nie techniczna): - „Quantum-ready” jako element pozycjonowania produktu w sektorze rządowym i obronnym. - Demonstracja innowacyjności wobec klientów STATE tier, którzy oczekują forward-looking technology roadmap. - Wyróżnienie się w procesach przetargowych, gdzie „quantum” jest buzzwordem w kryteriach oceny. - Budowa narracji przygotowania na przyszłość — klient kupuje nie tylko obecny produkt, ale i roadmapę.

Wartość biznesowa (mierzalna): - Post-quantum cryptography (PQC) — jedyna technologia kwantowa z realną, mierzalną wartością biznesową dla SYLION. Chroni przed harvest-now-decrypt-later. ROI: ochrona wieloletnich kontraktów STATE tier. - Quantum key distribution (QKD) — wartość teoretyczna dla fixed links, ale brak infrastruktury. ROI: zerowy w 2026, potencjalnie niezerowy po 2030. - Quantum computing dla optymalizacji — brak mierzalnej przewagi nad klasycznymi algorytmami w domenach SYLION (routing, scheduling, anomaly detection). ROI: zerowy.

Rekomendacja: 1. Inwestować w PQC (rozdziały 72–75) — realna ochrona, wymóg regulacyjny. 2. Komunikować „quantum-ready” w materiałach marketingowych — koszt minimalny (PQC i tak wdrażane), wartość marketingowa wysoka. 3. Nie inwestować w quantum computing ani QKD do czasu spełnienia kryteriów wejścia (77.5). 4. Monitorować — dedykowana osoba (Part-time R&D) śledzi postępy, raportuje kwartalnie. Koszt: ~ 0.1 FTE.

Ryzyko overhype: Komunikacja marketingowa musi być precyzyjna — „post-quantum cryptography” (prawda) vs „quantum-powered security” (nieprawda). Regulatorzy i audytorzy weryfikują twierdzenia techniczne. Fałszywe quantum claims mogą podważyć wiarygodność.

77.4 Pozycja w roadmapie — not before 2030

Status: [E] Eksperymentalny Odbiorca: CTO, Product Management, R&D Wpływ na baseline: Niski Powiązane rozdziały: 77.2, 77.5, 74.3

Quantum computing i QKD nie wchodzą do roadmapy SYLION przed 2030 rokiem. Jediną technologią kwantową w aktywnej roadmapie jest PQC (post-quantum cryptography), która jest kryptografią klasyczną odporną na ataki kwantowe.

Roadmapa kwantowa SYLION:

Rok	Działanie	Status
2026	PQC hybrid transport (IKEv2 + ML-KEM)	Aktywna implementacja
2027	PQC hybrid PKI (dual certificates)	Planowana
2028–2030	Full PQC (CNSA 2.0 exclusive)	Planowana
2028	QKD — re-evaluation point	Eksperymentalny review
2030+	Quantum computing — evaluation if fault-tolerant QC available	Nie w roadmapie

Uzasadnienie granicy 2030: - Prognozy dotyczące fault-tolerant quantum computing (NIST, NSA, Google Quantum AI) wskazują na horyzont 2030–2040 dla cryptographically relevant quantum computer (CRQC). - Brak komercyjnej infrastruktury QKD (sieci kwantowe, repeatery) przed 2030. - CNSA 2.0 nie wymaga quantum computing — wymaga PQC, co jest technologią klasyczną. - Koszty inwestycji w quantum computing R&D nie mają uzasadnienia biznesowego przy braku realnych use cases.

Re-evaluation triggers: Roadmapa jest rewizytowana jeśli którykolwiek trigger zostanie spełniony: 1. Ogłoszenie fault-tolerant quantum computer z >100 qubitów logicznych. 2. Komercyjna sieć QKD w Europie z zasięgiem >500 km. 3. Quantum computing as a service z SLA i certyfikacją bezpieczeństwa. 4. Klient STATE tier z konkretnym wymaganiem na quantum capability. 5. Regulacja wymagająca quantum technology (poza PQC).

Budżet R&D: 0.1 FTE na monitoring i kwartalny raport. Brak dedykowanego budżetu na implementację do czasu spełnienia kryteriów wejścia (77.5).

77.5 Kryteria wejścia do produkcji

Status: [E] Eksperymentalny Odbiorca: CTO, Architecture Board, R&D Wpływ na baseline: Niski Powiązane rozdziały: 77.2, 77.4, 91.1

Technologia kwantowa (quantum computing, QKD) może wejść do produkcji SYLION wyłącznie po spełnieniu wszystkich poniższych kryteriów. Kryteria są kumulatywne — wszystkie muszą być spełnione jednocześnie.

Kryteria techniczne:

Dostępność komercyjna — technologia dostępna od minimum 2 dostawców z SLA ≥99.9% i supportem komercyjnym. Brak vendor lock-in.

Certyfikacja — produkt/usługa posiada certyfikację FIPS 140-3 lub equivalent (Common Criteria EAL4+) dla security-relevant zastosowań. Dla QKD: certyfikacja ETSI QKD ISG lub equivalent.

Interoperability — technologia współpracuje z istniejącą infrastrukturą SYLION bez wymagania pełnego redesignu. Punkt integracji: zdefiniowane API, udokumentowany protokół.

Performance — overhead technologii kwantowej nie degraduje SLO SYLION. Latency budget: max +10% na operację wykorzystującą quantum capability.

Reliability — MTBF (Mean Time Between Failures) technologii kwantowej ≥10,000h. Fallback na klasyczne operacje musi być automatyczny i transparent dla użytkownika.

Kryteria biznesowe:

Use case — zidentyfikowany, zmierzony use case gdzie technologia kwantowa daje mierzalną przewagę nad rozwiązaniem klasycznym. „Mierzalna” = kwantyfikowalna poprawa (szybkość, bezpieczeństwo, koszt) udokumentowana w PoC.

ROI — pozytywny ROI w horyzoncie 24 miesięcy od wdrożenia. Koszt integracji + operacji < wartość dostarczona.

Popyt klienta — minimum 3 klientów (w tym ≥1 STATE tier) z wyrażonym zapotrzebowaniem na quantum capability.

Kryteria operacyjne:

Zespół — dostępność kompetencji w zespole (wewnętrznym lub partnerskim) do wdrożenia i utrzymania.

Monitoring — możliwość monitorowania health i performance quantum component standardowymi narzędziami (Prometheus, OpenTelemetry).

Disaster recovery — quantum component ma zdefiniowany DR plan z fallbackiem na klasyczne operacje.

Proces decyzyjny: Architecture Board ocenia kryteria. Decyzja: proceed to PoC / defer / reject. PoC w środowisku staging, 90 dni, z jasno zdefiniowanymi success criteria. Po PoC: go/no-go decision na production pilot.

Rozdział 78. Walidacja odporności post-quantowej

78.1 Testy zgodności — CNSA 2.0 checklist, FIPS 203/204/205

Status: [N] Normatywny Odbiorca: Compliance Officer, QA Engineer, Security Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 73.8, 74.10

Walidacja zgodności SYLION z wymaganiami postkwantowymi jest realizowana przez zestandaryzowane testy sprawdzające użycie algorytmów, parametrów i konfiguracji.

CNSA 2.0 Compliance Checklist:

ID	Wymaganie	Test	Kryterium pass/fail
CNSA-01	AES-256 dla szyfrowania symetrycznego	Audit cipher suite w IKEv2 i TLS	Tylko AES-256-GCM
CNSA-02	SHA-384+ dla hash	Audit hash algorithms w certyfikatach, IKEv2, TLS	SHA-384 lub SHA-512
CNSA-03	ML-KEM-1024 dla key establishment (STATE)	Przechwyt handshake IKEv2 i TLS, weryfikacja grupy	ML-KEM-1024 obecny
CNSA-04	ML-DSA-87 dla podpisów (STATE)	Weryfikacja algorytmu podpisu certyfikatów	ML-DSA-87 obecny
CNSA-05	P-384 dla klasycznej ECC (okres przejściowy)	Audit krzywej ECC	P-384 (nie P-256, nie Curve25519)
CNSA-06	FIPS 140-3 Level 3 HSM (STATE)	Certyfikat FIPS HSM	Level 3
CNSA-07	Brak zabronionych algorytmów	Scan CBOM	Brak RSA <3072, DH <3072, SHA-1, MD5

Testy FIPS 203 (ML-KEM): - Known Answer Tests (KAT) — weryfikacja implementacji ML-KEM z oficjalnymi wektorami testowymi NIST. - Generowanie klucza, enkapsulacja, dekapulacja — poprawność wynikowego shared secret. - Parametry: ML-KEM-768 (PRO), ML-KEM-1024 (STATE).

Testy FIPS 204 (ML-DSA): - KAT — weryfikacja podpisu i weryfikacji z wektorami NIST. - Podpis, weryfikacja, generowanie klucza — poprawność. - Parametry: ML-DSA-65 (PRO), ML-DSA-87 (STATE).

Testy FIPS 205 (SLH-DSA): - KAT — jak wyżej. - Parametry: SLH-DSA-SHA2-256s (jeśli używany dla Root CA).

Testy zgodności są uruchamiane w pipeline CI/CD jako blocking gate oraz kwartalnie jako audyt niezależny.

78.2 Testy wydajnościowe — latency benchmarks for hybrid handshake

Status: [N] Normatywny Odbiorca: QA Engineer, Network Engineer, Performance Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 74.9, 89.1

Testy wydajnościowe PQC mierzą narzut wprowadzony przez algorytmy postkwantowe w kluczowych przepływach SYLION.

Benchmarki handshake:

Test	Metryka	Target PRO	Target STATE
IKEv2 handshake (hybrydowy)	Latencja p50/p99	<70 ms / <100 ms	<75 ms / <110 ms
TLS 1.3 handshake (hybrydowy)	Latencja p50/p99	<40 ms / <60 ms	<45 ms / <70 ms
IKEv2 rekey (hybrydowy)	Latencja p50/p99	<60 ms / <90 ms	<65 ms / <100 ms
Certificate chain verification (hybrydowy)	Latencja	<10 ms	<15 ms

Benchmarki throughput:

Test	Metryka	Target
HSM ML-DSA-87 signing	ops/s	≥ 500
HSM ML-KEM-1024 decaps	ops/s	≥ 1000
IPsec ESP (AES-256-GCM)	Gbps	Bez degradacji vs klasyczny
TLS data transfer	Gbps	Bez degradacji vs klasyczny

Metodologia: - Narzędzia: ike-bench (custom), openssl s_time, iperf3, wrk (HTTP load). - Środowisko: izolowane VPS z profilem produkcyjnym (CPU, RAM, network). - Powtórzenia: 10.000 handshake’ów per test, statystyki p50/p95/p99. - Porównanie: baseline (klasyczny profil) vs hybrydowy vs pełny PQC.

Wyniki testów wydajnościowych są publikowane w raporcie migracji PQC i służą jako gate condition dla wdrożenia produkcyjnego.

78.3 Testy kompatybilności — interoperability with major TLS/IKEv2 stacks

Status: [N] Normatywny Odbiorca: QA Engineer, Network Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 74.9

Testy interoperacyjności potwierdzają, że implementacja PQC SYLION współpracuje z głównymi stosami kryptograficznymi i sprzętem sieciowym.

Matryca testów IKEv2:

Partner	Stack	ML-KEM support	Test
strongSwan ↔ strongSwan	libstrongswan + liboqs	Tak	Hybrydowy tunnel setup, rekey, failover
strongSwan ↔ Cisco IOS-XE	Cisco PQC	Tak (od IOS-XE 17.15)	Hybrydowy tunnel setup
strongSwan ↔ Palo Alto PAN-OS	Palo Alto PQC	Tak (od PAN-OS 11.2)	RFC 9370 ADD_KE
strongSwan ↔ FortiGate	FortiOS	Planowany	Fallback test

Matryca testów TLS 1.3:

Klient	Biblioteka	Hybrydowe grupy	Test
Chrome	BoringSSL	X25519Kyber768	Połączenie z SYLION proxy
Firefox	NSS	Planowane	Fallback test
curl (OpenSSL)	OpenSSL 3.x + oqs	x25519_mlkem768, p384_mlkem1024	Full test
Python requests	Python cryptography	Przez OpenSSL	API client test
Go net/http	Go crypto/tls	Eksperymentalne	API client test

Testy certyfikatów hybrydowych: - Weryfikacja dual-signature certyfikatu w OpenSSL, NSS, BoringSSL, Java keytool. - Test chain validation z hybrydowym Intermediate CA. - Test fallback: klient bez PQC weryfikuje klasyczny podpis, ignoruje PQC podpis.

Wyniki testów interoperacyjności są dokumentowane w macierzy kompatybilności, aktualizowanej przy każdym release.

78.4 Testy regresyjne — no classical crypto regression

Status: [N] Normatywny Odbiorca: QA Engineer, Security Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 81.5, 74.9

Dodanie algorytmów PQC nie może powodować regresji w bezpieczeństwie klasycznej kryptografii ani w funkcjonalności systemu.

Scenariusze regresji:

Downgrade attack — weryfikacja, że aktywacja hybrydowego profilu nie umożliwia wymuszenia wyłącznie klasycznego profilu przez atakującego (bez ML-KEM).

Test: MITM próba usunięcia ADDKE1 z IKE_SA_INIT — strongSwan musi odrzucić.

Cipher suite ordering — weryfikacja, że hybrydowe cipher suites mają wyższy priorytet niż klasyczne w negocjacji.

Fallback correctness — jeśli fallback do klasycznego profilu jest dozwolony (STANDARD tier), weryfikacja, że klasyczny profil nadal spełnia wymagania bezpieczeństwa (AES-256, SHA-384, ECDH P-384 lub Curve25519).

No PQC-only mode regression — po pełnej migracji PQC (Faza 3), weryfikacja, że nie ma ścieżki do ustanowienia sesji z wyłącznie klasycznym profilem.

Performance regression — brak degradacji throughput ESP/TLS po dodaniu PQC do handshake.

Certificate chain regression — poprawna weryfikacja istniejących klasycznych certyfikatów po dodaniu hybrydowych CA do trust store.

Testy regresyjne PQC są uruchamiane w pipeline CI/CD przy każdym release dotyczącym kryptografii, transportu lub PKI.

78.5 Testy integracji HSM

Status: [N] Normatywny Odbiorca: Security Engineering, QA, PKI Wpływ na baseline: Krytyczny Powiązane rozdziały: 75.1, 75.6, 88.5

Testy integracji HSM z PQC weryfikują poprawność operacji kryptograficznych post-quantum w środowisku HSM.

Zakres testów:

Functional tests: 1. ML-KEM key generation — generacja klucza ML-KEM-768 i ML-KEM-1024 w HSM → verify key metadata correct → verify key stored in HSM (non-exportable for STATE). 2. ML-KEM encapsulation/decapsulation — encapsulate → decapsulate → verify shared secret matches → verify timing consistent (no timing side-channels). 3. ML-DSA key generation — generacja klucza ML-DSA-65 i ML-DSA-87 w HSM → verify key metadata. 4. ML-DSA sign/verify — sign test data → verify signature → verify with external library (cross-implementation verification). 5. Hybrid operations — ECDSA + ML-DSA dual signature → verify both signatures valid → verify backward compatibility (classical verifier can verify ECDSA part).

Performance tests: 6. ML-KEM encapsulation throughput: measure operations/s → verify meets SLA per tier. 7. ML-DSA signing throughput: measure operations/s → compare with ECDSA baseline → document overhead. 8. Latency: measure single-operation latency for each PQC algorithm → verify within latency budget. 9.

Concurrency: 100 concurrent PQC operations → verify no degradation beyond expected.

Failure tests: 10. HSM unavailable during PQC operation → verify graceful failure, retry, failover to backup HSM. 11. Invalid PQC key material → verify HSM rejects, clear error message. 12. PQC algorithm not supported by HSM firmware → verify clear error, fallback to classical (with alert). 13. HSM firmware upgrade → verify PQC keys survive upgrade → verify operations resume post-upgrade.

Interoperability: 14. Key generated in HSM vendor A → used by software library (liboqs) → verify compatible. 15. Signature created by HSM → verified by OpenSSL + oqs-provider → verify successful.

Regression: Full HSM PQC test suite uruchamiany: po każdym HSM firmware upgrade, po każdej zmianie liboqs version, monthly scheduled.

78.6 Testy migracji — rollout and rollback

Status: [N] Normatywny Odbiorca: QA Engineer, DevOps, Network Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 74.9, 79.1

Testy migracji weryfikują poprawność procesów wdrażania i wycofywania PQC w środowisku produkcyjnym (na staging).

Scenariusze testowe:

Rolling PQC activation — aktywacja hybrydowego profilu na jednej bramce G1/G2, weryfikacja, że terminale z PQC negocjują hybrydowy handshake, terminale bez PQC negocjują klasyczny (dual-proposal).

Full PQC enforcement — usunięcie klasycznych propozycji, weryfikacja, że terminale bez PQC są odrzucane (IKE_SA_INIT NO_PROPOSAL_CHOSEN).

Rollback — transport — przywrócenie dual-proposal lub klasycznego profilu, weryfikacja, że wszystkie terminale odzyskują łączność w <5 minut.

Rollback — PKI — przywrócenie klasycznych certyfikatów z zapasowej hierarchii CA, weryfikacja chain validation.

Concurrent sessions — migracja jednej bramki podczas aktywnych sesji, weryfikacja, że istniejące sesje kontynuują z bieżącym kluczem (no session drop).

Cross-version interop — bramka z hybrydowym profilem ↔ bramka z klasycznym profilem — weryfikacja fallback.

Testy migracji są wykonywane w środowisku staging z pełnym profilem produkcyjnym (identyczna konfiguracja sieciowa, HSM, terminale).

78.7 Raportowanie wyników

Status: [N] Normatywny Odbiorca: CISO, Compliance, Architecture Wpływ na baseline: Wysoki Powiązane rozdziały: 78.1, 74.10, 91.1

Raportowanie wyników walidacji PQC zapewnia przejrzystość statusu migracji i gotowości post-quantum dla stakeholderów.

Format raportu:

PQC Readiness Report (kwartalny): 1. Executive summary — status migracji PQC per faza (74.3), % completion, key risks. 2. CNSA 2.0 compliance status — per requirement, per component: compliant / in-progress / not-started / not-applicable. 3. Algorithm inventory — CBOM update (74.2): which algorithms in use, where, classical vs hybrid vs full PQC. 4. Test results summary — compliance tests (78.1): pass/fail per test. Performance tests (78.2): latency benchmarks. Compatibility tests (78.3): interoperability matrix. HSM tests (78.5): functional verification. 5. Regression status — any regression introduced by PQC changes? Classical crypto still functioning correctly? 6. Migration progress — Gantt chart or timeline: planned vs actual per phase, milestones achieved, blockers. 7. Risk register — PQC-specific risks: algorithm changes, vendor support gaps, performance concerns, timeline risks. 8. Action items — open items from previous report, new items, owners, deadlines.

Odbiorcy i częstotliwość:

Raport	Odbiorca	Częstotliwość
PQC Readiness Report	CISO, CTO, Architecture Board	Kwartalnie
CNSA 2.0 Compliance Dashboard	Compliance, Sales (STATE tier)	Real-time (dashboard)
PQC Performance Benchmark	SRE, Architecture	Po każdej zmianie PQC config
Migration Status Update	Product Management, Sales	Miesięcznie (summary)

Automated reporting: - CNSA 2.0 compliance checklist automated — checks run daily, dashboard updated automatically. - Performance benchmarks automated — run in pipeline, results stored in time-series database, trends visible. - Algorithm inventory (CBOM) auto-generated from infrastructure scanning — no manual maintenance.

Audit evidence: Raporty archiwizowane w Zone 4 jako compliance evidence. Audytor zewnętrzny ma dostęp do dashboardu compliance. Raport pokrywa wymagania: ISO 27001 (A.10 Cryptography), CNSA 2.0 (per 74.10).

CZĘŚĆ IX — OPERACJE, WDROŻENIA I UTRZYMANIE

Rozdział 79. Strategie wdrożeniowe

79.1 Blue/Green — full environment swap, zero downtime

Status: [N] Normatywny Odbiorca: DevOps, SRE, Platform Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 79.2, 79.4, 80.6

Strategia Blue/Green polega na utrzymywaniu dwóch identycznych środowisk produkcyjnych (Blue — aktywne, Green — standby/przygotowane) i przełączeniu ruchu między nimi w momencie wdrożenia nowej wersji.

Implementacja w SYLION:

Środowisko Blue — bieżące produkcyjne, obsługujące 100% ruchu.

Środowisko Green — provisionowane z IaC (Terraform/Pulumi), identyczna konfiguracja, nowa wersja oprogramowania.

Pre-switch validation — Green przechodzi pełną walidację: smoke tests, security gates, health checks, synthetic transactions.

Switch — DNS-based (zmiana rekordu A/AAAA) lub load balancer-based (zmiana target group). Czas przełączenia: <5 minut (DNS TTL pre-set na 60s, LB instant).

Post-switch monitoring — 30-minutowy okres obserwacji z alertami na SLO breach.

Rollback — przełączenie ruchu z powrotem na Blue. Czas: <5 minut. Brak stanu współdzielonego (Blue zachowuje dane sprzed switch).

Zastosowanie w SYLION: Blue/Green jest preferowaną strategią dla komponentów bezstanowych: bramki G1/G2, reverse proxy, API zarządzania. Dla komponentów stanowych (Matrix homeserver, bazy danych) stosowane w połączeniu z migracją danych (patrz 79.6).

Koszty: Blue/Green wymaga podwójnej infrastruktury przez czas wdrożenia. Przy koszcie infrastruktury SYLION ~60 €/user/miesiąc, koszt Blue/Green dla 500 użytkowników to ~30.000 € dodatkowej infrastruktury na czas wdrożenia (typowo 1–4 godziny). Po walidacji, stare środowisko jest decommissionowane.

Wymagania: - IaC musi być w pełni deterministyczny — Green musi być identyczny z Blue poza wersją oprogramowania. - Brak mutowalnego stanu poza zdefiniowanymi źródłami (bazy danych, HSM, config store). - Monitoring musi wykrywać regresję w ciągu minut od przełączenia.

79.2 Canary — percentage traffic routing, automated rollback

Status: [N] Normatywny Odbiorca: DevOps, SRE, Platform Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 79.1, 80.6, 83.1

Canary deployment kieruje małą część ruchu (1–10%) do nowej wersji, porównuje metryki z baseline i automatycznie rozszerza lub wycofuje wdrożenie.

Implementacja w SYLION:

Canary instance — jedna lub kilka instancji z nową wersją, za load balancerem.

Traffic split — konfigurowany na LB (np. Envoy, HAProxy): 5% ruchu do canary, 95% do stable.

Metrics gate — automatyczna porównywarka metryk canary vs stable:

Error rate: canary $\leq 1.1 \times$ stable.

Latency p99: canary $\leq 1.2 \times$ stable.

Session success rate: canary $\geq 0.99 \times$ stable.

Automated promotion — jeśli metryki są w normie po 30 minutach, traffic split zwiększany: 5% → 25% → 50% → 100%.

Automated rollback — jeśli metryki breach threshold, canary jest natychmiast usuwany z LB, 100% ruchu wraca na stable. Alert P2 do on-call.

Zastosowanie w SYLION: Canary jest preferowaną strategią dla: - Session brokera (krytyczny component, risk-sensitive). - Matrix homeservera (stanowy, wymagający ostrożności). - CDR engine (potencjalne regresje w file processing).

Ograniczenia: - Canary wymaga wystarczającego ruchu do uzyskania statystycznie istotnych porównań. Dla małych wdrożeń (<50 użytkowników) canary może nie generować wystarczających danych — w takim przypadku stosujemy Blue/Green. - Session stickiness: jeśli użytkownik jest sticky do canary instance, bad experience trwa dłużej. Mitygacja: session-level canary z automatycznym re-routingiem przy degradacji.

79.3 Rolling — node-by-node update, HA maintained

Status: [N] Normatywny Odbiorca: DevOps, SRE Wpływ na baseline: Wysoki Powiązane rozdziały: 79.1, 79.2

Rolling deployment aktualizuje instancje jedna po drugiej (lub batch po batchu), utrzymując HA przez cały czas trwania wdrożenia.

Implementacja w SYLION:

Node selection — wybór instancji do aktualizacji: round-robin, najpierw least-loaded, lub random.

Drain — usunięcie instancji z pool LB, oczekiwanie na zakończenie aktywnych sesji (graceful drain, timeout: 60s dla HTTP, 300s dla VPN tunnels).

Update — aktualizacja oprogramowania na instancji (kontener replace, image swap, lub Firecracker microVM replace).

Health check — instancja musi przejść health check przed ponownym dodaniem do pool LB.

Readd — instancja wraca do pool, przyjmuje nowy ruch.

Next node — powtórzenie dla kolejnej instancji.

Parametry: - Max unavailable: 1 (zachowanie N-1 HA). - Health check interval: 5s. - Drain timeout: 300s (VPN sessions). - Rollback trigger: jeśli health check fails po aktualizacji 2 kolejnych instancji, zatrzymanie rollout, rollback zaktualizowanych instancji.

Zastosowanie w SYLION: Rolling jest strategią domyślną dla: - strongSwan bramek G1/G2 (sesje VPN wymagają drain). - Worker nodes (mikroserwisy, Firecracker host). - Monitoring stack.

79.4 Immutable replace — destroy old, provision new from IaC

Status: [N] Normatywny Odbiorca: DevOps, SRE, Security Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 79.1, 80.2

Immutable infrastructure oznacza, że żaden komponent produkcyjny nie jest modyfikowany in-place. Aktualizacja polega na zniszczeniu starej instancji i provisionowaniu nowej z IaC.

Zasady immutable infrastructure w SYLION:

Brak SSH/shell do produkcji — żaden inżynier nie loguje się do instancji produkcyjnej w celu modyfikacji. Wszelkie zmiany wymagają aktualizacji IaC, commit, review, pipeline, deploy.

Immutable images — kontenery Docker, obrazy Firecracker, VM images budowane w pipeline CI/CD. Obraz jest podpisany (ML-DSA) i promowany przez environments (dev → staging → prod).

Destroy before create (lub create before destroy) — Terraform/Pulumi tworzy nową instancję, przełącza ruch, niszczy starą. Brak mutowalnego stanu na instancji.

Ephemeral workloads — mikroVM operatorów (Firecracker) są z natury efemeryczne. Session start = create, session end = destroy. Brak persystencji między sesjami.

Wyjątki od immutability: - HSM — nie jest immutable (długoterminowe klucze, stan wewnętrzny). HSM jest aktualizowany przez firmware update, nie przez replace.

- Bazy danych — stan jest persystentny. Aktualizacja schematu przez migration, nie przez replace. Instancja DB może być replaced (HA failover do repliki), ale dane są migrowane. - Config store (Consul/Vault) — stan klastrowy. Aktualizacja przez rolling replace z zachowaniem quorum.

Korzyści bezpieczeństwa: Immutable replace eliminuje: configuration drift, persistence backdoors (backdoor nie przeżywa replace), nieudokumentowane zmiany. Każda instancja produkcyjna jest odtwarzalna z IaC — co jest fundamentem zarówno DR, jak i audytowalności.

79.5 Region failover — cross-region traffic routing

Status: [N] Normatywny Odbiorca: SRE, Network Engineer, Platform Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 84.4, 84.5

Region failover zapewnia ciągłość działania SYLION w przypadku awarii całego regionu (datacenter, availability zone, provider cloud).

Architektura multi-region SYLION:

Primary region — obsługuje 100% ruchu w normalnych warunkach. Pełna infrastruktura: bramki G1/G2, session broker, Matrix homeserver, management plane, HSM.

Secondary region — hot standby z replikowaną konfiguracją i danymi. Bramki G1/G2 w standby, replikowane polityki, synchronizowany state.

Mechanizm failover:

Detection — health check probe z zewnętrznego systemu monitoringu (np. Route53 health checks, Cloudflare Load Balancing health checks). Failure threshold: 3 consecutive failures w ciągu 30s.

DNS failover — zmiana rekordów DNS z primary IP na secondary IP. DNS TTL: 60s. Propagacja: 1–5 minut.

BGP failover (dla sovereign/dedicated) — zmiana ogłoszeń BGP, przełączenie routingu na secondary. Propagacja: <2 minuty.

Session re-establishment — operatorzy automatycznie re-establishują tunele IKEv2 do bramek w secondary region. Session broker przypisuje nowe mikroVM.

Data sync lag: Replikacja danych (Matrix messages, IAM state, policies) między regionami wprowadza opóźnienie. RPO per tier: - STATE: RPO 1h (synchronous lub near-synchronous replication). - PRO: RPO 4h (asynchronous replication). - STANDARD: RPO 24h (periodic backup).

Testowanie: Region failover jest testowany kwartalnie (tabletop) i rocznie (pełny failover techniczny). Wyniki dokumentowane, czas failover mierzony.

79.6 Tenant migration — move tenant between regions/clusters

Status: [R] Rekomendowany Odbiorca: Platform Engineer, SRE, Customer Success Wpływ na baseline: Średni Powiązane rozdziały: 79.5, 84.4

Migracja tenanta (operatora/klienta) między regionami lub klastrami może być wymagana z powodów regulacyjnych (data residency), wydajnościowych lub operacyjnych.

Procedura migracji tenanta:

Pre-migration assessment:

Weryfikacja docelowego regionu/klastra (pojemność, zgodność regulacyjna).

Identyfikacja danych do migracji: IAM state, polityki, konfiguracja środowisk, history Matrix (jeśli dotyczy).

Szacowanie okna migracji i wpływu na SLA.

Data replication:

Uruchomienie replikacji danych tenanta do docelowego regionu (asynchroniczna, z monitoringiem lag).

Replikacja konfiguracji i polityk (IaC apply w docelowym regionie).

Cutover:

Maintenance window komunikowany tenantowi (per SLA tieru).

Freeze na zapisy w źródłowym regionie.

Final sync (catch-up replication).

Przełączenie DNS/routing tenanta na docelowy region.

Walidacja: smoke tests, session establishment, Matrix connectivity.

Post-migration:

Monitoring przez 24h.

Decommissioning zasobów tenanta w źródłowym regionie (po okresie retencji).

Aktualizacja rejestrów: asset registry, tenant registry, CMDB.

Czas migracji: Zależny od ilości danych. Typowo: 1–4 godziny (okno maintenance), z 30-minutowym downtime cutover. Dla STATE: migracja w nocy, z dedykowanym wsparciem.

79.7 Upgrade between major versions — breaking change handling

Status: [N] Normatywny Odbiorca: DevOps, Platform Engineer, Product Owner Wpływ na baseline: Wysoki Powiązane rozdziały: 79.1, 79.8, 80.7

Aktualizacje między wersjami głównymi (major versions) mogą wprowadzać breaking changes: zmianę API, schematu danych, protokołów komunikacji, wymagań konfiguracyjnych.

Zasady obsługi breaking changes:

Deprecation period — nowa wersja major jest komunikowana z 6-miesięcznym wyprzedzeniem. Starszy API/protokół jest wspierany przez 1 release cycle (6–12 miesięcy) po wprowadzeniu nowej wersji.

Compatibility bridge — mosty kompatybilności tłumaczą stare API/format na nowe. Przykład: jeśli SYLION 3.0 zmienia format polityk z YAML na CUE, bridge automatycznie konwertuje stare polityki YAML.

Forced migration window — po upływie deprecation period, stary format/API jest wyłączany. Klienci, którzy nie zmigrowali, tracą funkcjonalność. Komunikacja: 90 dni, 30 dni, 7 dni, 1 dzień przed wyłączeniem.

Data migration — schema changes w bazach danych są realizowane przez migracje (Flyway/Alembic), uruchamiane automatycznie w pipeline deploy. Migracje są idempotentne, odwracalne (rollback migration), i testowane w staging.

Terminal firmware — aktualizacja firmware terminali operatorów jest krytyczna. SYLION wymusza minimalną wersję firmware (minimum supported version). Terminale poniżej minimalnej wersji nie mogą się połączyć.

Procedura major version upgrade: 1. Komunikacja (6 miesięcy przed). 2. Release candidate w staging (3 miesiące przed). 3. Early adopter program (2 miesiące przed, opt-in). 4. GA release. 5. Rolling upgrade per tier (STATE last, po walidacji na STANDARD/PRO). 6. Deprecation period (6–12 miesięcy). 7. End of life starej wersji.

79.8 Downtime policy — maintenance windows per tier SLA

Status: [N] Normatywny Odbiorca: SRE, Customer Success, Legal Wpływ na baseline: Krytyczny Powiązane rozdziały: 83.1, 85.1

Polityka downtime definiuje, kiedy planowany przestój jest dozwolony i jakie są wymagania komunikacyjne per tier.

Planned maintenance windows:

Tier	Okno maintenance	Częstotliwość	Notyfikacja
STANDARD	Sobota 02:00–06:00 CET	Max 1 ×/miesiąc	72h przed
PRO	Niedziela 02:00–04:00 CET	Max 1 ×/kwartał	7 dni przed
STATE	Negocjowane z klientem	Max 1 ×/kwartał	14 dni przed, zatwierdzenie klienta

SLA uptime targets:

Tier	SLO Uptime	Dozwolony downtime/miesiąc
STANDARD 99,5%	~22 minuty	
PRO 99,9%	~4,3 minuty	
STATE	99,95%	~4,3 minuty (negocjowalne do 99,999%)

Zasady: - Planned maintenance nie wlicza się do SLA downtime, jeśli odbywa się w oknie maintenance i jest skomunikowany zgodnie z wymaganiami. - Unplanned downtime zawsze wlicza się do SLA. - Emergency maintenance (security patch, P1 hotfix) jest dozwolony poza oknem maintenance z notyfikacją best-effort (min. 1h, ideally 4h). Wlicza się do SLA chyba że patch adresuje aktywny exploit.

Rozdział 80. CI/CD i pipeline dostarczania

80.1 Pipeline logic — build → test → security gates → signing → deploy → validate

Status: [N] Normatywny Odbiorca: DevOps, Security Engineer, Software Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 80.2–80.10

Pipeline CI/CD SYLION implementuje model „shift-left security” z obligatoryjnymi bramkami bezpieczeństwa na każdym etapie.

Etapy pipeline:

1. Source → 2. Build → 3. Test → 4. Security Gates → 5. Artifact Signing → 6. Promotion → 7. Deploy (staging) → 8. Validate → 9. Deploy (prod) → 10. Post-deploy

Każdy etap jest atomiczny — failure na dowolnym etapie blokuje pipeline. Brak „skip” ani override (poza break-glass, patrz 80.8).

Szczegóły etapów:

Source — commit trigger (Git push), PR merge. Pre-commit hooks: linting, format check.

Build — budowanie artefaktów w hermetycznym środowisku (patrz 80.2).

Test — unit, integration, contract (patrz 80.3).

Security Gates — SAST, SCA, secret scanning, license compliance (patrz 80.4).

Artifact Signing — podpis artefaktu kluczem HSM (patrz 80.5).

Promotion — promowanie artefaktu do registry wyższego poziomu (dev → staging → prod).

Deploy (staging) — wdrożenie w staging, pełne smoke tests.

Validate — E2E tests, security regression, performance regression na staging.

Deploy (prod) — wdrożenie w produkcji (Blue/Green, Canary, Rolling — per component).

Post-deploy — monitoring 30-minutowy, walidacja SLO, automated rollback trigger.

Immutability pipeline: Pipeline jest definiowany as-code (GitLab CI, GitHub Actions, lub Tekton) w repozytorium chroniony branch protection. Zmiana pipeline wymaga code review + CISO approval (dla security gates).

80.2 Build — reproducible builds, hermetic environments

Status: [N] Normatywny Odbiorca: DevOps, Software Engineer Wpływ na baseline: Wysoki Powiązane rozdziały: 80.1, 80.5

Budowanie artefaktów SYLION musi być reprodukowalne (reproducible) i hermetyczne (hermetic) — dwa identyczne buildy z tego samego source powinny produkować binarnie identyczne artefakty.

Zasady reproducible builds:

Hermetic environment — build odbywa się w izolowanym kontenerze z pinowanymi wersjami narzędzi (compiler, linker, runtime). Brak dostępu do internetu podczas build — wszystkie zależności pre-fetched.

Dependency pinning — wszystkie zależności (biblioteki, pakiety, moduły) zablokowane na konkretne wersje z weryfikowanymi hash (SHA-256). lock file (package-lock.json, Cargo.lock, go.sum, poetry.lock) jest commitowany do repozytorium.

Deterministic output — eliminacja źródeł niedeterminizmu: timestamps, random seeds, file ordering, path dependencies. Build timestamp: ustawiony na commit timestamp.

SBOM generation — przy każdym build generowany jest SBOM (Software Bill of Materials) w formacie SPDX lub CycloneDX. SBOM zawiera: wszystkie zależności, ich wersje, licencje, hashes.

Weryfikacja reprodukowalności — dla artefaktów krytycznych (bramki G1/G2, HSM client, terminal firmware) wykonywany jest dual-build: dwa niezależne buildy z tego samego source, porównanie binarnych artefaktów.

Artefakty SYLION: - Kontenery Docker (OCI images). - Obrazy Firecracker (rootfs + kernel). - Firmware terminali. - Pakiety konfiguracji (polityki, IaC modules).

80.3 Test — unit, integration, contract, security scan

Status: [N] Normatywny Odbiorca: QA Engineer, Software Engineer, DevOps Wpływ na baseline: Wysoki Powiązane rozdziały: 80.1, 81.1, 92.1

Etap testowy pipeline CI/CD obejmuje wielowarstwowy zestaw testów uruchamianych automatycznie.

Piramida testów SYLION:

Warstwa	Typ testu	Target pokrycia	Czas wykonania
Baza	Unit tests	≥80% line coverage	<5 minut
Środek	Integration tests	Kluczowe przepływy	<15 minut
Środek	Contract tests	Wszystkie API boundaries	<10 minut
Szczyt	Security scans	100% kodu	<20 minut

Unit tests: Każdy komponent ma unit tests pokrywające logikę biznesową, walidację, transformację danych. Minimum 80% line coverage, 90% dla komponentów security-critical (auth, crypto, policy engine).

Integration tests: Testowanie interakcji między komponentami w izolowanym środowisku (Docker Compose lub Kind). Kluczowe przepływy: session establishment, IAM authentication, policy evaluation, CDR pipeline.

Contract tests: Consumer-driven contract tests (Pact) dla API boundaries. Każdy konsument API definiuje kontrakt (oczekiwane request/response), producent weryfikuje zgodność. Zapobiega breaking changes w API wewnętrznych.

Security scans (w ramach test stage): - Dependency vulnerability scan (Trivy, Gype). - Basic SAST (semgrep — quick rules). - Pełne security gates w osobnym etapie (80.4).

80.4 Security gates — SAST, SCA, secret scanning, license compliance

Status: [N] Normatywny Odbiorca: Security Engineer, DevOps, CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 80.1, 80.3, 90.1

Security gates są obligatoryjnymi bramkami bezpieczeństwa w pipeline CI/CD. Failure na dowolnej bramce blokuje pipeline.

Bramki bezpieczeństwa:

SAST (Static Application Security Testing):

Narzędzia: Semgrep (primary), CodeQL (secondary).

Zasady: custom SYLION rules + community rules.

Blocking: Critical i High findings blokują pipeline.

False positive management: allowlist z wymaganym justification i review.

SCA (Software Composition Analysis):

Narzędzia: Trivy, Grype, Dependabot.

Blocking: CVE z CVSS ≥ 7.0 blokuje pipeline. CVE ≥ 9.0 wymaga immediate fix.

Grace period: CVE z CVSS 7.0–8.9 — 14 dni na fix/mitigation. CVE ≥ 9.0 — brak grace period.

Secret scanning:

Narzędzia: TruffleHog, GitLeaks.

Blocking: każdy wykryty secret (API key, password, private key) blokuje pipeline.

Remediation: rotacja skompromitowanego sekretu, usunięcie z historii Git (git filter-branch), alert do SOC.

License compliance:

Narzędzia: FOSSA, licensechecker.

Blocking: licencje copyleft (GPL, AGPL) w zależnościach komercyjnych blokują pipeline.

Dozwolone: MIT, Apache 2.0, BSD, ISC.

IaC security scan:

Narzędzia: Checkov, tfsec.

Blocking: Critical i High findings w konfiguracji Terraform/Pulumi.

Wyniki security gates są raportowane w artifact metadata i dostępne w audycie CI/CD.

80.5 Artifact promotion — immutable artifacts, signed tags

Status: [N] Normatywny Odbiorca: DevOps, Security Engineer Wpływ na baseline: Krytyczny Powiązane rozdziały: 80.1, 80.2, 75.4

Artefakty SYLION są immutable i podpisywane kryptograficznie na każdym etapie promocji.

Model promocji artefaktów:

Build Registry (dev) → Staging Registry → Production Registry | | | sign (ML-DSA-65) | verify + re-sign | verify | tag: sha256-xxx | tag: staging-v3.2.1 | tag: prod-v3.2.1

Podpis artefaktu: - Narzędzie: cosign (Sigstore) z kluczem HSM (PKCS#11). - Algorytm: ML-DSA-65 (PRO) / ML-DSA-87 (STATE). W okresie przejściowym: dual-sign ECDSA + ML-DSA. - Podpis obejmuje: hash artefaktu (SHA-384), SBOM, metadata (build ID, commit SHA, pipeline URL).

Kryteria promocji: - dev → staging: wszystkie testy pass, security gates pass, podpis artefaktu valid. - staging → prod: E2E tests pass, performance regression pass, security regression pass, approval (manual lub automated per policy).

Immutability: Artefakt w registry jest immutable — nie może być nadpisany, usunięty ani zmodyfikowany. Tag jest unikatowy i powiązany z jednym artefaktem.

Wszelka próba nadpisania jest logowana i alertowana.

Provenance chain: Każdy artefakt posiada provenance chain: commit SHA → build ID → test results → security scan results → signature → promotion events.

Provenance jest weryfikowalna end-to-end: od kodu źródłowego do instancji produkcyjnej.

80.6 Deployment gates — environment health checks, canary metrics

Status: [N] Normatywny Odbiorca: DevOps, SRE Wpływ na baseline: Wysoki Powiązane rozdziały: 79.2, 80.1, 83.1

Deployment gates walidują stan środowiska docelowego i metryki wdrożenia przed i po deploy.

Pre-deployment gates: 1. Environment health — wszystkie komponenty docelowego środowiska healthy (health endpoint 200 OK). 2. Capacity check — docelowe środowisko ma wystarczającą pojemność (CPU, RAM, storage) dla nowej wersji. 3. Policy validation — polityki bezpieczeństwa w docelowym środowisku są aktualne i zgodne z profilem. 4. Pending incidents — brak otwartych incydentów P1/P2 w docelowym środowisku.

Post-deployment gates (canary/rolling): 1. Error rate — $\leq$ baseline $\times 1.1$ przez 15 minut. 2. Latency — P99 latency $\leq$ baseline $\times 1.2$ przez 15 minut. 3. Success rate — request success rate $\geq 99.9\%$ w canary traffic. 4. Session stability — brak wzrostu session drops w canary traffic. 5. Security events — brak nowych alertów security w canary traffic. 6. Resource consumption — CPU/RAM nowej wersji w ramach budżetu ($\pm 10\%$ baseline).

Automated gate evaluation: Pipeline automatycznie ewaluuje metryki z systemu monitoringu (Prometheus/Grafana). Jeżeli jakiegokolwiek gate fails, deployment jest wstrzymywany i alertowany. W trybie canary, traffic jest wycofywany do poprzedniej wersji. W trybie rolling, kolejne node'y nie są aktualizowane.

Manual gate override: W wyjątkowych przypadkach (np. krytyczny hotfix), autoryzowana osoba (SRE Lead + Security Lead) może nadpisać gate failure z uzasadnieniem. Override jest logowany w audit trail z identyfikacją osoby, uzasadnieniem i ticket referencją.

80.7 Release approvals — who approves what, automation vs manual

Status: [N] Normatywny Odbiorca: DevOps, Product Management, Security Wpływ na baseline: Wysoki Powiązane rozdziały: 80.1, 80.6, 85.7

Release approvals definiują, kto i kiedy zatwierdza wdrożenie do poszczególnych środowisk. Model jest zróżnicowany w zależności od risk level zmiany i środowiska docelowego.

Macierz zatwierdzeń:

Środowisko	Typ zmiany	Approval
dev/staging	Dowolna	Automatyczna (po passing gates)
prod (patch)	Bug fix, security patch	DevOps Lead (automated after gates)
prod (minor)	Nowa funkcjonalność	Product Owner + DevOps Lead
prod (major)	Breaking change, migracja	Product Owner + CTO + Security Lead
prod (emergency)	Critical security fix	Dual approval: DevOps Lead + Security Lead
STATE tenant	Dowolna	Dodatkowy approval: Compliance Officer

Automatyzacja approvals: Dla zmian niskiego ryzyka (patch, staging), approval jest automatyczny po spełnieniu wszystkich gates. System generuje approval record z timestamp i gate results. Dla zmian wyższego ryzyka, system wysyła request o approval do odpowiednich osób przez Slack/email z deadline (2h dla prod minor, 24h dla major).

Approval audit trail: Każdy approval (automatyczny i manualny) jest logowany: kto zatwierdził, kiedy, na jakiej podstawie, jakie gates przeszły, jaki artefakt jest wdrażany. Audit trail jest immutable i przechowywany w Zone 4.

80.8 Emergency releases — break-glass pipeline, dual approval

Status: [N] Normatywny Odbiorca: DevOps, SRE, Security Wpływ na baseline: Krytyczny Powiązane rozdziały: 80.7, 85.3, 96.1

Emergency releases (hotfix) obsługują sytuacje wymagające natychmiastowego wdrożenia — zero-day vulnerability, krytyczna awaria produkcyjna, wyciek danych. Pipeline emergency jest uproszczony, ale zachowuje minimalne wymagania bezpieczeństwa.

Emergency pipeline: 1. Hotfix branch — tworzony z aktualnego tagu produkcyjnego (nie z develop). 2. Build — standardowy build z reproducibility guarantees. 3. Skrócone testy — unit tests + security regression tests (pominięte E2E jeśli czas krytyczny, ale wymagane w ciągu 24h po deploy). 4. Security scan — SAST + SCA mandatory nawet w emergency. 5. Dual approval — DevOps Lead + Security Lead muszą zatwierdzić. Brak single-person deploy w emergency. 6. Deploy — bezpośrednio canary → full rollout (pominięty staging jeśli czas krytyczny). 7. Post-deploy validation — health checks + error rate monitoring natychmiast po deploy.

Break-glass criteria: Emergency pipeline jest dostępny wyłącznie gdy: - Istnieje otwarty incydent P1 lub P2 z security impactem. - CVE z CVSS ≥ 9.0 dotyczy komponentu produkcyjnego. - Aktywna eksploatacja potwierdzona przez SOC. - Autoryzacja pisemna (nawet Slack message jest akceptowalna) od CTO lub CISO.

Post-emergency obligations: W ciągu 24h od emergency deploy: pełne testy E2E, staging verification, audit trail review. W ciągu 72h: post-mortem z RCA (Root Cause Analysis), lessons learned, update procedur jeśli potrzebny.

80.9 Rollbacks — automated rollback triggers, manual rollback

Status: [N] Normatywny Odbiorca: DevOps, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 79.1, 79.2, 80.6, 84.10

Rollback przywraca system do poprzedniej wersji w przypadku awarii wdrożenia lub degradacji. SYLION wspiera zarówno automated jak i manual rollback.

Automated rollback triggers: - Error rate > 2× baseline przez 5 minut. - P99 latency > 3× baseline przez 5 minut. - Health check failures na >20% instancji. - Security alert wygenerowany w kontekście nowej wersji. - Canary metrics poza SLO przez 10 minut.

Procedura automated rollback: 1. Alert wystawiony do SRE team (P2 min.). 2. Traffic natychmiast redirected do starej wersji (Blue/Green: przełączenie LB; Canary: 100% na stable). 3. Nowa wersja wstrzymana (instancje nie są jeszcze usuwane — zachowane do diagnostyki). 4. Metryki potwierdzają powrót do baseline. 5. Post-mortem ticket automatycznie tworzony.

Manual rollback: SRE może zainicjować manual rollback w dowolnym momencie. Procedura: 1. Komenda rollback w deployment tool (z justification w komentarzu). 2. System wykonuje te same kroki co automated rollback. 3. Justification logowany w audit trail.

State cleanup: Po rollback, system sprawdza: - Database migrations — jeśli wykonane, wymagany rollback migration lub forward-fix. - Configuration changes — automatyczny rollback do previous config version. - Feature flags — automatycznie wyłączone flagi włączone w nowej wersji. - Cache invalidation — cache’y mogą wymagać flush po rollback.

Ograniczenia rollback: Niektóre zmiany nie podlegają automatycznemu rollback: migracje schematu bazy danych, zmiany w formacie danych persystentnych, zmiany w API kontraktach z zewnętrznymi systemami. Te zmiany wymagają planowania rollback strategii przed wdrożeniem (np. backward-compatible migrations, dual-write patterns).

80.10 CI/CD audit trail — pipeline provenance, immutable logs

Status: [N] Normatywny Odbiorca: DevOps, Security, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 80.1, 80.7, 80.8, 93.1

Każdy element pipeline CI/CD generuje immutable audit trail, przechowywany w Zone 4 i niedostępny do modyfikacji przez operatorów pipeline.

Co jest logowane: - Każdy build: trigger (commit SHA, branch, user), parametry, dependencies resolved, SBOM wygenerowany. - Każdy test run: wyniki, coverage, czas trwania, failures. - Każdy security scan: findings, severity, disposition (fixed, accepted, deferred). - Każdy approval: kto, kiedy, na jakiej podstawie. - Każdy deployment: artefakt, środowisko, strategia, wynik. - Każdy rollback: trigger (automated/manual), justification, wynik. - Każdy access do pipeline secrets: kto, kiedy, jaki sekret.

Artifact provenance chain: Dla każdego artefaktu produkcyjnego istnieje pełna provenance chain:

commit → build → tests → scans → signature → approval → deploy → validation

Każdy krok jest podpisany cyfrowo (ML-DSA w tierze STATE, ECDSA w STANDARD/PRO). Provenance jest weryfikowalna przez audytora bez dostępu do pipeline — wystarczy dostęp do provenance store w Zone 4.

Retencja: Audit trail CI/CD przechowywany minimum 5 lat. Dla STATE tier: 10 lat lub zgodnie z wymaganiami regulatora. Dane przechowywane w immutable storage (WORM) z integrality checksums.

Compliance mapping: - SOC 2: CC8.1 (Change Management) — pipeline audit trail satisfies evidence requirements. - ISO 27001: A.12.1.2 (Change Management) — documented, approved, tested changes. - CNSA 2.0: provenance chain potwierdza użycie zatwierdzonych algorytmów kryptograficznych w podpisach.

Rozdział 81. Automatyzacja testów kontraktowych i regresyjnych

81.1 Contract testing — consumer-driven contracts (Pact)

Status: [R] Rekomendowany Odbiorca: Developers, QA, DevOps Wpływ na baseline: Wysoki Powiązane rozdziały: 80.3, 88.1, 88.8

Testy kontraktowe weryfikują, że interfejsy między serwisami SYLION pozostają zgodne po zmianach. Model consumer-driven (Pact) zapewnia, że provider nie złamie oczekiwań consumera.

Zasada: Consumer definiuje kontrakt — oczekiwane request/response pary. Provider weryfikuje, że spełnia kontrakt. Jeżeli provider zmienia API w sposób niezgodny z kontraktem, test fails i deploy jest blokowany.

Kluczowe kontrakty w SYLION: - Session broker ↔ G2 gateway (session setup, teardown, heartbeat). - G2 gateway ↔ policy engine (authorization decisions). - Management plane ↔ IAM (user provisioning, role assignment). - Workload ↔ Matrix (message routing, presence, key exchange). - HSM ↔ PKI service (key generation, signing, certificate issuance). - SIEM collector ↔ telemetry pipeline (event format, schema).

Workflow: 1. Consumer generuje pact file (JSON/protobuf schema oczekiwanych interakcji). 2. Pact file publikowany do Pact Broker (centralne repozytorium kontraktów). 3. Provider pipeline pobiera kontrakty i weryfikuje je w fazie test. 4. Wynik weryfikacji publikowany do Pact Broker z statusem (pass/fail). 5. Deployment gate sprawdza Pact Broker: deploy dozwolony tylko jeśli wszystkie kontrakty verified.

Wersjonowanie kontraktów: Kontrakty są wersjonowane per-consumer-version. Provider musi spełniać kontrakty wszystkich aktywnych consumer versions (N i N-1 minimum). Deprecation kontraktu wymaga powiadomienia consumera z minimum 30 dni notice.

81.2 Integration regression — regresja integracyjna

Status: [N] Normatywny Odbiorca: QA, DevOps Wpływ na baseline: Wysoki Powiązane rozdziały: 80.3, 87.1, 88.1

Testy regresji integracyjnej uruchamiają pełny zestaw testów integracji po każdej zmianie w komponencie, weryfikując, że zmiana nie złamała istniejących integracji.

Zakres: Każdy komponent SYLION posiada integration test suite obejmujący wszystkie interfejsy wejścia/wyjścia. Test suite jest uruchamiany: - Po każdym merge do main branch. - Przed każdym deployment do staging. - Codziennie jako scheduled regression (nightly build).

Środowisko testowe: Integration regression wykonywany w dedykowanym środowisku integracyjnym, odizolowanym od dev i staging. Środowisko jest odtwarzane z IaC przed każdym test run (ephemeral environment) lub utrzymywane jako stable integration z codziennym reset.

Kryteria pass/fail: - 100% integration tests musi pass (brak tolerancji na failures). - Test duration ≤ 30 minut (SLA na feedback loop). - Flaky tests (niestabilne) są flagowane i muszą być naprawione w ciągu 7 dni lub usunięte z gating suite.

81.3 Session flow regression — regresja przepływów sesyjnych

Status: [N] Normatywny Odbiorca: QA, DevOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 87.2, 87.3, 89.3

Testy regresji przepływów sesyjnych weryfikują kompletne ścieżki operatora w systemie: od logowania przez nawiązanie sesji, pracę w sesji, aż do zakończenia.

Kluczowe scenariusze: 1. Login → session → work → logout: Operator loguje się przez G1, nawiązuje sesję przez broker, pracuje w środowisku workload, wylogowuje się gracefully. 2. Login → session → disconnect → reconnect: Operator traci połączenie sieciowe, reconnect automatyczny, sesja kontynuowana bez utraty stanu. 3. Login → session → timeout → re-auth: Sesja wygasa (idle timeout), operator re-autentykuje się, odzyskuje sesję. 4. Multi-session: Operator nawiązuje wiele sesji jednocześnie (max per policy). 5. Session z CDR: Transfer pliku przez CDR pipeline — upload, sanitization, download. 6. Session z voice/video: Połączenie głosowe/wideo przez Matrix, sprawdzenie jakości (latency, jitter).

Automatyzacja: Testy sesyjne są w pełni zautomatyzowane (headless browser/client automation). Każdy test mierzy: - Czas nawiązania sesji (SLO: ≤ 5 sekund). - Czas odpowiedzi aplikacji w sesji (SLO: ≤ 200ms P99). - Stabilność sesji (zero unexpected disconnects w 30-minutowym teście).

81.4 Security regression — re-run all security tests

Status: [N] Normatywny Odbiorca: Security, QA Wpływ na baseline: Krytyczny Powiązane rozdziały: 80.4, 90.1, 92.6

Testy regresji bezpieczeństwa uruchamiają pełny zestaw testów security po każdej zmianie, weryfikując, że żaden mechanizm ochrony nie został osłabiony.

Zakres: - SAST re-scan — pełny static analysis na zmienionym kodzie i jego dependencies. - SCA re-scan — sprawdzenie nowych dependency vulnerabilities (CVE check). - Secret scanning — weryfikacja, że żadne sekrety nie wyciekły do kodu/konfiguracji. - Policy regression — OPA/Rego policies przetestowane na zbiorze test cases (pozytywne i negatywne). - TLS configuration — weryfikacja cipher suites, protocol versions, certificate chains. - Authentication flows — testy mechanizmów auth (MFA, SSO, token expiry). - Authorization rules — RBAC/ABAC rules przetestowane na macierzy przypadków.

Gating: Security regression jest blocking gate — jakkolwiek failure blokuje deployment. Brak wyjątków nawet dla emergency releases (emergency pipeline wymaga minimum SAST + SCA + secret scan).

Raportowanie: Wyniki security regression są publikowane do security dashboard i załączane do artefaktu deployment jako evidence. Dla STATE tier, wyniki są podpisane cyfrowo i archiwizowane w Zone 4.

81.5 Infrastructure regression — IaC plan diff, drift detection

Status: [R] Rekomendowany Odbiorca: DevOps, SRE Wpływ na baseline: Wysoki Powiązane rozdziały: 82.8, 79.4, 97.6

Testy regresji infrastrukturalnej weryfikują, że zmiany w Infrastructure as Code nie wprowadzają nieoczekiwanych modyfikacji w środowisku.

Plan diff: Przed każdym zastosowaniem zmian IaC (Terraform/OpenTofu plan), system generuje diff — zestawienie planowanych zmian. Diff jest: - Automatycznie analizowany pod kątem destrukcyjnych zmian (destroy/replace resources). - Porównywany z listą oczekiwanych zmian z PR description. - Flagowany jeśli zawiera zmiany w security groups, network rules, IAM policies, encryption settings.

Drift detection: System codziennie porównuje stan faktyczny infrastruktury z deklarowanym w IaC: - Resource configuration drift (np. security group rule dodana ręcznie). - Tag drift (brakujące lub zmienione tagi). - Secret rotation drift (expired secrets/certificates). Drift jest alertowany i musi być zaadresowany w ciągu 24h (remediation: apply IaC lub update IaC do aktualnego stanu z justification).

Blast radius analysis: Dla każdej zmiany IaC system szacuje blast radius — ile tenantów, sesji, komponentów jest potencjalnie affected. Zmiany z dużym blast radius (>50% tenantów) wymagają dodatkowego approval.

81.6 Policy regression — policy evaluation correctness

Status: [N] Normatywny Odbiorca: Security, DevOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 82.4, 90.7, 92.5

Testy regresji polityk weryfikują, że OPA/Rego policies zwracają poprawne decyzje dla zdefiniowanego zbioru test cases.

Test suite: Każda polityka posiada zbiór test cases: - Positive tests — request, który powinien być dozwolony, jest dozwolony. - Negative tests — request, który powinien być zablokowany, jest zablokowany. - Edge cases — graniczne przypadki (np. expired token, partially matching role). - Regression tests — przypadki dodane po bugach (każdy bug w policy = nowy test case).

Automated evaluation: Policy test suite jest uruchamiany: - Po każdej zmianie w policy repository. - Jako gate w CI/CD pipeline (blocking). - Codziennie jako scheduled regression.

Policy versioning: Każda zmiana policy jest wersjonowana (Git). Diff między wersjami jest reviewowany przez Security team. Policy nie może być zmieniona bez review i approval.

Coverage: Minimum 95% branch coverage dla critical policies (access control, session authorization). Coverage mierzona narzędziami OPA (opa test –coverage).

81.7 Data migration regression

Status: [R] Rekomendowany Odbiorca: Developers, QA, Database Engineering Wpływ na baseline: Wysoki Powiązane rozdziały: 79.7, 84.1, 81.1

Data migration regression testy weryfikują, że migracje danych (schema changes, data transforms, platform upgrades) nie powodują utraty, korupcji ani niespójności danych.

Scenariusze:

Schema migration: 1. Forward migration — zastosuj migrację schema (Flyway, Liquibase, Alembic) → verify schema correct → verify existing data accessible → verify new features work → verify no data loss. 2. Backward migration (rollback) — rollback schema migration → verify schema returned to previous state → verify data intact → verify old version of application works. 3. Idempotency — zastosuj migrację 2× → verify no error, no duplicate data, no schema corruption.

Data transformation: 4. Data integrity post-transform — before/after row counts, checksum comparison, sample data verification. 5. Encoding/format changes — verify character encoding preserved (UTF-8), date formats correct, numeric precision maintained. 6. NULL handling — verify NULL values handled correctly in migration (not silently converted to empty strings or zeros).

Large dataset migration: 7. Performance at scale — migration time for production-like dataset (millions of rows) → verify within maintenance window (per 79.8). 8. Concurrent access during migration — online migration (zero-downtime schema change) → verify reads and writes work during migration → verify no locking issues. 9. Partial failure — migration fails mid-way (simulate disk full, timeout) → verify clean rollback → verify no partial state.

Cross-component migration: 10. IAM data migration — user accounts, roles, policies migrated → verify all users can authenticate post-migration → verify permissions correct. 11. PKI data migration — certificates, CRL, OCSP data migrated → verify certificate chain valid → verify no expired/revoked certs incorrectly active. 12. Telemetry data migration — logs, metrics migrated to new store → verify queryability → verify retention policies applied correctly.

Testing approach: Migration tests executed in staging with production-like dataset (anonymized). Pre/post checksums mandatory. Automated regression suite verifies application functionality after every migration. Migration without passing regression = blocked.

Rozdział 82. Zarządzanie konfiguracją i feature flags

82.1 Model konfiguracji — declarative, versioned, audited

Status: [N] Normatywny Odbiorca: DevOps, SRE, Security Wpływ na baseline: Krytyczny Powiązane rozdziały: 80.10, 81.5, 82.8

Konfiguracja SYLION jest zarządzana deklaratywnie — pożądany stan jest zdefiniowany w kodzie (Git), a system konwerguje do tego stanu automatycznie. Żadna zmiana konfiguracji nie odbywa się manualnie na serwerze.

Zasady: - Deklaratywność — konfiguracja opisuje „co” (desired state), nie „jak” (imperative steps). - Wersjonowanie — każda zmiana jest commit w Git z message, autorem, review. - Audytorowalność — pełna historia zmian, kto, kiedy, dlaczego. - Immutability — config jest aplikowany jako całość (nie partial updates). Każdy deploy stosuje pełny config. - Reproducibility — identyczny config produkuje identyczny stan środowiska.

Struktura konfiguracji:

config/ |—— base/ # wspólna konfiguracja |—— overlays/ | |—— standard/ # per tier | |—— pro/ | |—— state/ |—— tenants/ | |—— tenant-abc/ # per tenant overrides | |—— tenant-xyz/ |—— secrets/ # encrypted, HSM-backed references

Walidacja: Każda zmiana config jest walidowana w CI pipeline: - Schema validation (JSON Schema / CUE). - Policy validation (OPA — czy config nie narusza security policies). - Dry-run apply (Terraform plan / Kubernetes dry-run). - Diff review (zmiana wyświetlona w PR).

82.2 Static vs dynamic config

Status: [N] Normatywny Odbiorca: DevOps, Developers Wpływ na baseline: Średni Powiązane rozdziały: 82.1, 82.4, 82.8

Rozróżnienie między konfiguracją statyczną (wymagającą redeploy) a dynamiczną (zmienianą at runtime) jest kluczowe dla operacji SYLION.

Static config (deploy-time): - Wersje obrazów kontenerów / VM. - Struktura sieci (subnets, security groups, firewall rules). - Parametry HSM (endpoint, slot ID, key aliases). - TLS/IPsec konfiguracja (cipher suites, certificate paths). - Resource limits (CPU, RAM per workload type).

Dynamic config (runtime): - Feature flags (włączanie/wyłączanie funkcjonalności). - Rate limits (per tenant, per endpoint). - Maintenance mode (per tenant, per region). - Alert thresholds (adjustable without redeploy). - Log level (debug/info/warn/error — adjustable at runtime dla diagnostyki).

Zasady bezpieczeństwa: - Dynamic config nie może zmieniać security posture (np. wyłączyć MFA, zmienić cipher suite). - Zmiany security-affecting config muszą być static (deploy-time) z pełnym CI/CD pipeline. - Dynamic config changes są logowane w audit trail z identyfikacją osoby i justification. - Dynamic config posiada rate limit na zmiany (max 10 zmian/godzinę per scope) jako ochrona przed config storms.

82.3 Secret vs non-secret config

Status: [N] Normatywny Odbiorca: DevOps, Security Wpływ na baseline: Krytyczny Powiązane rozdziały: 75.1, 82.1, 93.1

Konfiguracja SYLION dzieli się na jawną (non-secret) i tajną (secret). Traktowanie ich jest fundamentalnie różne.

Non-secret config: - Przechowywana w Git (plaintext). - Reviewowana w PR (widoczna dla developerów). - Deployowana jako część standardowego pipeline. - Przykłady: porty serwisów, nazwy endpointów, parametry timeoutów, log levels.

Secret config: - Nigdy nie przechowywana w plaintext w repozytorium. - Przechowywana w Vault (HashiCorp Vault) lub HSM. - Referencja w konfiguracji: vault:secret/data/syilion/prod/db-password — system w runtime pobiera wartość. - Rotation: automatyczna (gdzie możliwa) lub scheduled z alertem. - Access control: principle of least privilege — każdy serwis ma dostęp wyłącznie do swoich sekretów. - Audit: każdy dostęp do sekretu jest logowany (kto, kiedy, jaki sekret, z jakiego serwisu).

Typy sekretów w SYLION: - Database credentials (rotation co 90 dni). - API keys do integracji zewnętrznych. - TLS private keys (zarządzane przez cert-manager lub HSM, nie ręcznie). - HSM PINs (przechowywane w procedurze ceremonialowej, nie w systemie). - Encryption keys (zarządzane przez HSM, nigdy eksportowane). - Service account tokens (krótkotrwałe, auto-renewed).

Zero-secret-in-code policy: CI pipeline skanuje każdy commit pod kątem przypadkowego umieszczenia sekretów (secret scanning — TruffleHog, GitLeaks). Wykrycie sekretu blokuje merge i wymaga immediate rotation.

82.4 Feature flags governance — who can enable, per-tenant, rollout %

Status: [R] Rekomendowany Odbiorca: Product, DevOps, Security Wpływ na baseline: Średni Powiązane rozdziały: 82.2, 82.5, 82.6

Feature flags umożliwiają kontrolowane włączanie funkcjonalności bez wdrażania nowego kodu. W SYLION, feature flags podlegają ścisłemu governance ze względu na implikacje bezpieczeństwa.

Typy flag: - Release flag — kontroluje widoczność nowej funkcji (temporary, usuwana po full rollout). - Operational flag — kontroluje zachowanie operacyjne (np. rate limit adjustment, maintenance mode). - Experiment flag — A/B testing (ograniczone zastosowanie w systemie security-focused). - Permission flag — per-tenant feature enablement (np. PQC hybrid mode for specific tenant).

Governance: - Każda nowa flaga wymaga PR z opisem: co kontroluje, kto jest owner, kiedy ma być usunięta (expiry date). - Security-affecting flags (np. dotyczące auth, crypto, access control) wymagają review Security team. - Flaga bez expiry date lub nieużywana >90 dni jest automatycznie flagowana do usunięcia. - Maksymalna liczba aktywnych flag: 50 (zapobiega flag explosion i nieczytelności konfiguracji).

Per-tenant enablement: Feature flags mogą być włączane per-tenant, umożliwiając: - Early access dla wybranych tenantów. - Różne feature sets dla różnych tierów (STANDARD/PRO/STATE). - Wyłączenie problematycznej funkcji dla konkretnego tenanta.

Rollout %: Flagi mogą być ustawione na procent tenantów (np. 10% → 25% → 50% → 100%). Rollout jest monitorowany — wzrost error rate powoduje automatyczne cofnięcie rollout percentage.

82.5 Safe rollout — gradual, with metrics

Status: [R] Rekomendowany Odbiorca: DevOps, Product Wpływ na baseline: Średni Powiązane rozdziały: 79.2, 82.4, 83.1

Bezpieczny rollout feature flags odbywa się stopniowo z monitorowaniem metryk na każdym etapie.

Procedura: 1. Canary (1-5%) — włączenie flagi dla 1-5% tenantów. Monitoring przez 24h. Sprawdzenie: error rate, latency, session stability, support ticket volume. 2. Early majority (25%) — rozszerzenie na 25% tenantów. Monitoring 48h. Sprawdzenie jw. + resource consumption. 3. Majority (50%) — rozszerzenie na połowę. Monitoring 24h. 4. Full rollout (100%) — pełne włączenie. Monitoring 7 dni. 5. Cleanup — usunięcie flagi z kodu (feature jest teraz stałą częścią systemu).

Automatic rollback: Na każdym etapie, jeżeli metryki wykraczają poza zdefiniowane thresholds, system automatycznie cofa rollout do poprzedniego poziomu i alertuje team.

Metrics gates per stage: - Error rate: $\leq$ baseline + 0.1%. - Latency P99: $\leq$ baseline $\times$ 1.15. - Session drops: $\leq$ baseline + 0.01%. - Support tickets: $\leq$ baseline + 10% (manual check).

82.6 Kill switches — immediate disable, no code deploy needed

Status: [N] Normatywny Odbiorca: SRE, Security, DevOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 82.4, 95.3, 97.8

Kill switches to specjalna kategoria feature flags, które mogą natychmiast wyłączyć funkcjonalność bez wdrażania kodu. Są krytycznym mechanizmem operacyjnym.

Zasady: - Każda nowa major feature musi posiadać kill switch (wymaganie review checklist). - Kill switch musi działać w czasie $\leq$ 30 sekund od aktywacji (propagacja do wszystkich instancji). - Aktywacja kill switch nie wymaga deploy — zmiana w config store (etcd/Consul) propagowana natychmiast. - Kill switch log: kto aktywował, kiedy, powód (mandatory justification field).

Pre-defined kill switches w SYLION: - kill.cdr.processing — wyłączenie CDR pipeline (pliki blokowane do ręcznego review). - kill.voice.video — wyłączenie voice/video (Matrix fallback do text-only). - kill.external.integrations — wyłączenie integracji zewnętrznych. - kill.new.sessions — blokada nowych sesji (istniejące

kontynuowane). - kill.file.upload — blokada upload plików. - kill.pqc.hybrid — fallback do classical crypto (jeśli PQC powoduje problemy).

Autoryzacja: Kill switch aktywacja dostępna dla: SRE Lead, Security Lead, CTO, CISO. Dual approval nie jest wymagany (czas reakcji jest krytyczny), ale post-activation review w ciągu 4h jest obowiązkowy.

82.7 Tenant-specific config

Status: [N] Normatywny Odbiorca: DevOps, Account Management Wpływ na baseline: Średni Powiązane rozdziały: 82.1, 82.4, 85.9

Każdy tenant SYLION może mieć konfigurację specyficzną, nadpisując defaults dla danego tieru.

Co może być tenant-specific: - Feature flags (per-tenant enablement). - Rate limits (custom limits per umowie). - Data residency (region restriction). - Session parameters (idle timeout, max sessions per user). - CDR policy (custom sanitization rules per tenant agreement). - Branding (logo, colors — dla tenantów z custom portal). - Integration endpoints (custom SSO IdP, custom SIEM target).

Co NIE może być tenant-specific: - Security baselines (minimum TLS version, minimum cipher strength, MFA requirement). - Audit logging (zawsze enabled, tenant nie może wyłączyć). - Encryption at rest (zawsze AES-256, nie konfigurowalny). - Zero Trust architecture fundamentals (nie można „wyłączyć” zero trust dla tenanta).

Hierarchia konfiguracji:

Global defaults → Tier defaults → Tenant overrides → Environment overrides

Każdy poziom może nadpisać niższy, ale nigdy nie może osłabić security baseline. System waliduje tenant config pod kątem security constraints przed zastosowaniem.

82.8 Drift detection and remediation

Status: [N] Normatywny Odbiorca: SRE, Security Wpływ na baseline: Wysoki Powiązane rozdziały: 81.5, 82.1, 97.6

Configuration drift oznacza rozbieżność między deklarowanym (desired) a faktycznym (actual) stanem systemu. SYLION aktywnie wykrywa i remediuje drift.

Typy drift: - Infrastructure drift — zasoby infrastrukturalne (VM, sieci, storage) różnią się od deklaracji IaC. - Config drift — parametry konfiguracyjne na instancjach różnią się od config store. - Policy drift — polityki wdrożone różnią się od tych w repozytorium. - Certificate drift — certyfikaty zbliżają się do wygaśnięcia lub mają nieoczekiwane parametry. - Secret drift — sekrety nie były rotowane zgodnie z polityką.

Wykrywanie: - Infrastructure drift: Terraform/OpenTofu plan w trybie detect (codziennie, automated). - Config drift: agent na instancjach porównuje local config z config store (co 5 minut). - Policy drift: OPA policy bundle hash porównywany z repozytorium (co minutę). - Certificate drift: cert-manager monitoring (ciągły). - Secret drift: Vault audit log + rotation policy check (codziennie).

Remediacja: - Auto-remediation dla low-risk drift (np. config drift → automatic reapply from config store). - Alert + manual review dla high-risk drift (np. infrastructure drift → manual terraform apply after review). - Immediate alert + investigation dla security drift (np. nieoczekiwana zmiana security group rule). - Drift jest logowany jako security event w Zone 4.

Rozdział 83. Monitoring, alertowanie i SLO/SLA

83.1 SLI/SLO model — Service Level Indicators and Objectives

Status: [N] Normatywny Odbiorca: SRE, Product, Account Management Wpływ na baseline: Krytyczny Powiązane rozdziały: 83.2, 83.7, 83.8

SLI (Service Level Indicators) to metryki mierzące jakość usługi z perspektywy użytkownika. SLO (Service Level Objectives) to target values dla tych metryk.

Kluczowe SLI SYLION:

SLI	Definicja	Pomiar
Availability	% czasu, gdy system akceptuje i obsługuje requesty	Uptime - planned maintenance
Session setup latency	Czas od request do aktywnej sesji	P50, P95, P99
Request latency	Czas odpowiedzi API management plane	P50, P95, P99
Error rate	% requestów z kodem błędu (5xx)	Rolling 5-minute window
Session stability	% sesji bez nieoczekiwanego disconnectu w ciągu godziny	Rolling 1h window
Data integrity	% operacji, gdzie dane nie zostały uszkodzone	Checksum validation

SLO per tier:

SLI	STANDARD	PRO	STATE
Availability	99.95% (26 min/month)	99.95% (4.3 min/month)	99.95% (4.3 min/month)
Session setup latency (P99)	≤ 8s	≤ 5s	≤ 3s
Request latency (P99)	≤ 500ms	≤ 300ms	≤ 200ms
Error rate	≤ 0.1%	≤ 0.05%	≤ 0.01%
Session stability	≥ 99.9%	≥ 99.95%	≥ 99.95%
Data integrity	100%	100%	100%

Pomiar: SLI mierzone przez syntetyczny monitoring (external probes) i real-user monitoring (RUM). Oba źródła porównywane — rozbieżność > 5% wymaga investigation.

83.2 Error budgets — how calculated, how consumed

Status: [N] Normatywny Odbiorca: SRE, Product, Engineering Leadership Wpływ na baseline: Wysoki Powiązane rozdziały: 83.1, 83.3, 80.7

Error budget to dopuszczalny margines niedostępności wynikający z SLO. Error budget = 1 - SLO. Dla STANDARD (99.5%): error budget = 0.05% = ~26 minut/miesiąc.

Kalkulacja:

Error budget (minuty/miesiąc) = 43200 × (1 - SLO) STANDARD: 43200 × 0.0005 = 21.6 min PRO/STATE: 43200 × 0.0001 = 4.32 min

Konsumpcja: Error budget jest konsumowany przez: - Planowane maintenance (odliczane z budżetu, ale schedulowane w oknie maintenance). - Nieplanowane incydenty (downtime, degradacja). - Deployments causing errors (canary failures, rollback time).

Policy based on budget consumption: | Consumption | Action | | 0-50% | Normal development velocity. Feature releases allowed. | | 50-75% | Caution. Risk review for each deployment. | | 75-90% | Slow down. Only low-risk deployments. Focus on reliability. | | 90-100% | Freeze. Only critical security patches. All engineering focus on reliability. | | >100% | SLO breached. Post-mortem required. Customer credit triggered. |

Raportowanie: Error budget consumption jest widoczny na executive dashboard w real-time. Weekly report do Engineering Leadership. Monthly report do klientów (dla tierów z SLA reporting).

83.3 Alert severity — P1/P2/P3/P4 definitions

Status: [N] Normatywny Odbiorca: SRE, NOC, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 83.4, 85.8, 95.1

Alerty SYLION są klasyfikowane w czterech poziomach severity, determinujących czas reakcji i eskalację.

Definicje:

Priority	Definicja	Przykłady	Czas reakcji	Czas rozwiązania
P1 Critical	Pełna niedostępność usługi lub naruszenie bezpieczeństwa	Region down, data breach, HSM compromise, >50% sessions failed	5 min (alert) → 15 min (response)	≤ 1h mitigation, ≤ 4h resolution
P2 High	Znacząca degradacja usługi	Partial outage, >10% session failures, security vulnerability exploited	15 min (alert) → 30 min (response)	≤ 4h mitigation, ≤ 24h resolution
P3 Medium	Ograniczona degradacja, workaround dostępny	Single component degraded, elevated error rate, non-critical cert expiring	1h (alert) → 4h (response)	≤ 24h resolution
P4 Low	Anomalia bez wpływu na usługę	Performance drift, non-critical log warning, upcoming maintenance	Next business day	≤ 1 week

Reguły: - Alert P1/P2 automatycznie powiadamia on-call (PagerDuty/Opsgenie). - P1 eskalowany do Engineering Manager po 30 min bez mitigation, do CTO po 1h. - P2 eskalowany po 2h bez mitigation. - P3/P4 obsługiwane w godzinach pracy (dla STANDARD tier; PRO/STATE mają 24/7 coverage). - Security incidents są zawsze minimum P2 (P1 jeśli active exploitation).

83.4 Ownership model — who owns which alerts, on-call rotation

Status: [N] Normatywny Odbiorca: SRE, Engineering Leadership Wpływ na baseline: Wysoki Powiązane rozdziały: 83.3, 85.4, 95.4

Każdy alert w SYLION ma jasno zdefiniowanego ownera — team odpowiedzialny za response.

Ownership mapping:

Komponent	Alert Owner	Escalation
G1 gateway	Network Team	SRE Lead → CTO
G2 gateway	Network Team	SRE Lead → CTO
Session broker	Platform Team	SRE Lead → CTO
Workload (microVM)	Platform Team	SRE Lead → CTO
Matrix core	Platform Team	SRE Lead → CTO
HSM/PKI	Security Team	CISO → CTO
IAM/SSO	Identity Team	Security Lead → CISO
CDR pipeline	Security Team	Security Lead → CISO
Management plane	Platform Team	SRE Lead → CTO
Infrastructure (network, DNS, storage)	Infrastructure Team	SRE Lead → CTO
Security events (SOC alerts)	SOC Team	CISO → CEO

On-call rotation: - Każdy team ma on-call rotation (min. 4 osoby w rotacji, 1-tydzień shift). - Primary on-call + secondary backup. - Dla STATE tier: follow-the-sun rotation (multi-timezone coverage). - On-call engineer musi odpowiedzieć na P1/P2 w ciągu 15 minut (alertem, nie rozwiązaniem). - Compensation: on-call bonus + time-off for incidents requiring after-hours work.

Runbook coupling: Każdy alert posiada link do runbook. On-call engineer zaczyna od runbook. Jeśli runbook nie rozwiązuje problemu, eskalacja do next level.

83.5 Dashboards — executive, operational, security, tenant-visible

Status: [N] Normatywny Odbiorca: SRE, Security, Product, Customers Wpływ na baseline: Średni Powiązane rozdziały: 83.1, 83.7, 93.2

SYLION utrzymuje cztery kategorie dashboardów dostosowanych do odbiorców.

Executive dashboard: - SLO compliance per tier (monthly trend). - Error budget consumption (real-time). - Active incidents (count by severity). - Customer satisfaction (ticket volume, resolution time). - Cost per user per tier (monthly). Aktualizacja: real-time, z 5-minutowym rolling window.

Operational dashboard: - Per-component health (green/yellow/red). - Request rate, error rate, latency (P50/P95/P99). - Session count, session failures, reconnect rate. - Infrastructure utilization (CPU, RAM, storage, network per region). - Deployment status (last deploy, canary status, rollback history). Aktualizacja: real-time, 15-sekundowy scrape interval.

Security dashboard: - Active security alerts (by severity, by type). - WAF/IDS events (blocked requests, suspicious patterns). - Certificate status (expiry countdown, rotation status). - Vulnerability scan results (open CVEs, time to remediate). - Policy compliance status (drift, violations). Aktualizacja: real-time, z historycznym widokiem 30-dniowym.

Tenant-visible dashboard: - Uptime status per service (operational, degraded, outage). - Recent incidents affecting tenant (last 30 days). - SLA report (monthly availability vs SLO). - Planned maintenance schedule. - No internal details — tenant widzi wyłącznie metryki jakości usługi, nie wewnętrzną architekturę.

83.6 NOC/SOC interplay — infrastructure vs security

Status: [N] Normatywny Odbiorca: NOC, SOC, SRE, Security Wpływ na baseline: Wysoki Powiązane rozdziały: 83.3, 83.4, 95.5

NOC (Network Operations Center) odpowiada za dostępność i wydajność infrastruktury. SOC (Security Operations Center) odpowiada za bezpieczeństwo i detekcję zagrożeń. Ich współpraca jest kluczowa.

Podział odpowiedzialności:

Typ zdarzenia	Primary	Secondary	Escalation
Infrastructure outage	NOC	SRE	CTO
Performance degradation	NOC	SRE	Engineering Lead
Security alert (SIEM)	SOC	Security Team	CISO
DDoS attack	NOC + SOC (joint)	SRE + Security	CTO + CISO
Data breach	SOC	Legal + Compliance	CISO + CEO
Certificate expiry	NOC	Security Team	SRE Lead
Suspicious access pattern	SOC	IAM Team	CISO

Escalacja krzyżowa: - NOC wykrywa anomalie infrastrukturalną, która może mieć podłoże security → eskalacja do SOC. - SOC wykrywa attack, który powoduje infrastructure impact → eskalacja do NOC. - Joint incident: NOC Lead + SOC Lead wspólnie koordynują response.

Komunikacja: - Dedykowany kanał komunikacji NOC→SOC (Slack channel, phone bridge). - Dla P1/P2 incydentów: wspólny war room (wirtualny lub fizyczny). - Post-incident review obejmuje oba zespoły.

83.7 Tenant-visible status — status page, incident notifications

Status: [N] Normatywny Odbiorca: Account Management, Customers Wpływ na baseline: Średni Powiązane rozdziały: 83.5, 84.9, 85.4

Każdy tenant SYLION ma dostęp do strony statusu prezentującej aktualny stan usługi i historię incydentów.

Status page: - Komponent-level status: Management Plane, Session Service, Voice/Video, File Transfer, Authentication. - Trzy stany: Operational (zielony), Degraded Performance (żółty), Outage (czerwony). - Automatyczna aktualizacja na podstawie synthetic monitoring. - Historia incydentów z ostatnich 90 dni. - Planned maintenance calendar.

Incident notifications: - Automatyczne powiadomienie email/webhook do zarejestrowanych kontaktów tenanta. - P1: powiadomienie w ciągu 15 minut od wykrycia. - P2: powiadomienie w ciągu 30 minut. - Update co 30 minut podczas aktywnego P1, co 1h podczas P2. - Resolution notification z preliminary root cause. - Post-mortem published w ciągu 5 dni roboczych (P1) lub 10 dni (P2).

SLA transparency: Tenant może w dowolnym momencie sprawdzić: - Aktualny SLA compliance (% uptime w bieżącym miesiącu). - Historyczny SLA compliance (ostatnie 12 miesięcy). - Incydenty, które wpłynęły na SLA. - Ewentualne SLA kredyty (automatycznie obliczane).

83.8 SLA reporting — automated monthly reports, credits

Status: [N] Normatywny Odbiorca: Account Management, Finance, Customers Wpływ na baseline: Średni Powiązane rozdziały: 83.1, 83.7, 85.1

System automatycznie generuje miesięczne raporty SLA dla każdego tenanta i oblicza kredyty za naruszenia SLO.

Raport SLA zawiera: - Okres raportowy (miesiąc kalendarzowy). - Uptime percentage (measured vs SLO target). - Lista incydentów wpływających na tenanta (z czasem trwania, impact description). - Planned vs unplanned downtime breakdown. - SLO compliance per SLI (availability, latency, error rate). - Trend comparison z poprzednim miesiącem i 3-miesięcznym rolling average.

Credit calculation:

SLO breach	Credit
< 0.01% miss (99.95% → 99.98%)	5% monthly fee
0.01-0.1% miss	10% monthly fee
0.1-1% miss	25% monthly fee
> 1% miss	50% monthly fee
> 5% miss (catastrophic)	100% monthly fee + incident review

Automatyzacja: - Raport generowany automatycznie 1-go dnia miesiąca za poprzedni miesiąc. - Kredyty obliczane automatycznie i dodawane do faktury (no customer action required). - Raport wysyłany do głównego kontaktu tenanta i dostępny na portalu klienta. - Wewnętrznie: raport review przez Account Manager przed publikacją (weryfikacja edge cases, np. maintenance window agreement).

Rozdział 84. Backup, DR i ciągłość działania

84.1 Co backupujemy — configuration, policies, IAM state, PKI

Status: [N] Normatywny Odbiorca: SRE, DevOps, Security Wpływ na baseline: Krytyczny Powiązane rozdziały: 84.2, 84.3, 84.10

Strategia backupu SYLION obejmuje wyłącznie dane niezbędne do odtworzenia systemu — zgodnie z zasadą, że system jest odtwarzalny z IaC + backupu konfiguracji.

Co podlega backupowi:

Kategoria	Dane	Częstotliwość	Retencja
IaC state	Terraform/OpenTofu state files	Po każdym apply	1 rok
Configuration	Config store (etcd/Consul snapshot)	Co 1h	90 dni
IAM state	User accounts, roles, policies, group memberships	Co 1h	1 rok
PKI (non-secret)	Certificates, CRLs, OCSP responder data	Co 6h	Lifecycle certyfikatu + 1 rok
Policy store	OPA policies, Rego bundles	Po każdym deploy	1 rok
Management plane DB	Tenant metadata, asset registry, audit pointers	Co 1h	1 rok
Audit logs	Zone 4 immutable logs	Continuous (replication)	Per policy (5-10 lat)
DNS configuration	Zone files, DNSSEC keys	Co 24h	90 dni
Monitoring configuration	Alert rules, dashboard definitions, runbooks	Po każdej zmianie	1 rok

Zasady: - Backup musi być szyfrowany at rest (AES-256) i in transit (TLS 1.3). - Backup musi być przechowywany w innym regionie niż primary (cross-region). - Backup musi być testowany (restore test) — patrz 84.5. - Backup credentials oddzielone od production credentials (odrębne konto, odrębny klucz).

84.2 Czego NIE backupujemy — session keys, communication content

Status: [N] Normatywny Odbiorca: SRE, Security, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 84.1, 72.4, 82.3

Architektura SYLION celowo wyklucza pewne dane z backupu — ze względów bezpieczeństwa, prywatności i designu systemu.

Co NIE jest backupowane:

Dane	Powód
Session keys (ephemeral)	Keys istnieją wyłącznie w RAM microVM, nigdy persystowane. Są per-session i nie przeżywają restartu by design.
Communication content (E2EE)	SYLION nie posiada kluczy do odszyfrowania treści. Operator kontroluje swoje dane. Backup treści jest odpowiedzialnością operatora, nie platformy.
HSM private keys	Klucze prywatne nigdy nie opuszczają HSM. Backup HSM odbywa się poprzez HSM-native backup mechanism (encrypted backup to secondary HSM).
Workload ephemeral state	MicroVM workloady są ephemeral — state nie jest persystowany poza sesją. Odtworzenie = nowa microVM z clean image.
Temporary files in CDR pipeline	Pliki w CDR pipeline są przetwarzane i przekazywane. Temporary copies usuwane po przetworzeniu. Nie podlegają backupowi.
Vault unseal keys	Master key / unseal keys przechowywane w procedurze ceremonialowej (Shamir’s Secret Sharing), nie w backup systemie.

Implikacje: - Session restoration after disaster: operator musi nawiązać nową sesję (brak session resume z backupu). - Communication history: jeśli klient wymaga archiwizacji komunikacji, musi to zaimplementować po swojej stronie (SYLION dostarcza export API, ale nie archiwizuje treści). - HSM recovery: wymaga procedury ceremonialowej z udziałem key custodians.

84.3 RPO/RTO per tier

Status: [N] Normatywny Odbiorca: SRE, Account Management, Customers Wpływ na baseline: Krytyczny Powiązane rozdziały: 84.1, 84.4, 84.10

RPO (Recovery Point Objective) i RTO (Recovery Time Objective) definiują akceptowalną utratę danych i czas odtworzenia.

Tier	RPO	RTO	Implikacja backup
STANDARD	24h	4h	Backup co 24h wystarczający. Odtworzenie z ostatniego daily backup.
PRO	4h	2h	Backup co 1h (zapas). Odtworzenie z ostatniego hourly backup.
STATE	1h	1h	Backup co 15 min (zapas). Odtworzenie z ostatniego backup + WAL replay. Warm standby w secondary region.

RPO calculation basis: RPO dotyczy danych, które SYLION backupuje (84.1). Dla treści E2EE (84.2) — RPO jest odpowiedzialnością klienta. Platform RPO obejmuje: - Konfigurację (utrata max RPO minut zmian config). - IAM state (utrata max RPO minut user/role changes). - Audit logs (continuous replication — effective RPO ≈ 0 for audit data).

RTO breakdown: RTO obejmuje pełen cykl: detection → decision → restore → validation → traffic cutover. Poszczególne fazy: - Detection: ≤ 5 min (automated monitoring). - Decision: ≤ 15 min (automated or on-call decision). - Restore: region-dependent (warm standby: ≤ 15 min; cold restore: ≤ 2h). - Validation: ≤ 15 min (automated smoke tests). - Cutover: ≤ 5 min (DNS/LB switch).

84.4 Region strategy — primary + secondary, data residency

Status: [N] Normatywny Odbiorca: SRE, Compliance, Account Management Wpływ na baseline: Krytyczny Powiązane rozdziały: 79.5, 84.3, 84.6

SYLION operuje w modelu multi-region z primary i secondary region per tenant.

Model: - Primary region: obsługuje 100% traffic tenanta. Pełna infrastruktura (G1, G2, broker, workloads, HSM, management plane). - Secondary region: warm standby (STATE tier) lub cold standby (PRO/STANDARD). Przechowuje repliki backupów i konfiguracji. - Failover: automatyczny (STATE) lub manual (PRO/STANDARD).

Data residency: Dane tenanta nigdy nie opuszczają zdefiniowanego regionu (np. EU, DACH, PL) bez jawnej zgody. Backup cross-region jest wykonywany do regionu w ramach tej samej strefy residency. Przykład: tenant PL ma primary w Warszawa, secondary w Frankfurt — oba w EU.

Replication: | Dane | Replication mode | Lag | |—|—| | Configuration | Synchronous (STATE) / Async (PRO) | ≤ 1s / ≤ 1min | | IAM state | Async | ≤ 5 min | | Audit logs | Async (continuous) | ≤ 1 min | | PKI | Sync (STATE) / Manual (PRO) | ≤ 1s / daily | | Monitoring data | Not replicated (local per region) | N/A |

Region selection: Tenant wybiera primary region przy onboarding. Zmiana primary region jest możliwa (tenant migration — 79.6), ale wymaga planned maintenance window i data migration.

84.5 Restore validation — automated testing

Status: [N] Normatywny Odbiorca: SRE, DevOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 84.1, 84.3, 84.7

Backup bez testowania restore jest bezwartościowy. SYLION wykonuje regularne testy odtwarzania.

Automated restore test (weekly): 1. Pobranie ostatniego backupu z backup storage. 2. Odtworzenie do izolowanego środowiska testowego (nie production). 3. Walidacja integrity: row counts, checksum, constraint validation. 4. Uruchomienie smoke tests na odtworzonym środowisku. 5. Weryfikacja, że management plane UI jest dostępny i functional. 6. Zmierzenie czasu odtworzenia (actual vs RTO target). 7. Raport z wyników (automated, wysłany do SRE Lead).

Full DR exercise (quarterly): Pełne ćwiczenie disaster recovery obejmujące: - Failover do secondary region. - Odtworzenie z backupu w secondary region. - Smoke tests + full E2E session test. - Pomiar RTO/RPO (actual vs target). - Dokumentacja wyników i lessons learned.

Kryteria sukcesu: - Restore time ≤ target RTO. - Data loss ≤ target RPO. - All smoke tests pass. - No data corruption detected. - Jeśli kryteria nie spełnione: P2 incident, corrective actions required within 14 days.

84.6 Immutable backups — WORM storage, retention lock

Status: [N] Normatywny Odbiorca: SRE, Security, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 84.1, 84.5, 93.1

Backupy SYLION są przechowywane w trybie immutable (Write-Once-Read-Many), zapobiegającym modyfikacji lub usunięciu — nawet przez administratorów.

WORM storage: - Backup storage skonfigurowany z retention lock (Object Lock w S3-compatible storage lub WORM tape). - Retention period ustawiony per backup type (90 dni — 10 lat). - Po ustawieniu retention lock, nikt nie może usunąć ani zmodyfikować backup przed upływem retention. - Retention lock jest compliance mode (nie governance mode) — nawet root account nie może usunąć.

Credentials isolation: - Backup storage credentials oddzielone od production credentials. - Backup write credentials nie mają read access do production. - Production credentials nie mają delete access do backup storage. - Break-glass access do backup (np. extended retention) wymaga dual approval + justification.

Integrity verification: - Każdy backup posiada checksum (SHA-384). - Checksum przechowywany w oddzielnym store (integrity manifest). - Weekly automated verification: backup checksum vs manifest. - Anomalia (checksum mismatch) alertowana jako P1 security incident.

84.7 DR exercises — tabletop quarterly, technical DR annually

Status: [N] Normatywny Odbiorca: SRE, Security, Engineering Leadership Wpływ na baseline: Wysoki Powiązane rozdziały: 84.5, 95.7, 96.1

Ćwiczenia DR (Disaster Recovery) weryfikują gotowość organizacji i infrastruktury do odtworzenia po katastrofie.

Tabletop exercise (quarterly): - Scenariusz: opisowa symulacja katastrofy (np. „region EU-WEST-1 niedostępny przez awaria providera”, „ransomware na management plane”). - Uczestnicy: SRE, Security, Product, Account Management, Engineering Leadership. - Przebieg: moderator prezentuje scenariusz → zespoły decydują o krokach → moderator wprowadza complications → ocena decyzji. - Output: lista gaps w procedurach, action items z deadline, updated runbooks.

Technical DR exercise (annually): - Full failover do secondary region. - Restore z backup + verification. - E2E session test z synthetic tenants. - Pomiar actual RTO/RPO. - Simulacja communication (customer notification, status page update). - Post-exercise report z comparison actual vs target.

Chaos engineering (STATE tier, quarterly): - Kontrolowane zakłócenia w production (kill random node, inject latency, simulate HSM failure). - Self-healing verification (97.1-97.7). - Bounded blast radius (nigdy więcej niż 1 tenant/region affected). - Rollback procedure zawsze gotowa.

84.8 Business continuity — what continues during partial outage

Status: [N] Normatywny Odbiorca: SRE, Product, Account Management Wpływ na baseline: Wysoki Powiązane rozdziały: 84.7, 84.9, 84.10

Plan ciągłości działania definiuje, które usługi SYLION kontynuują działanie podczas częściowego outage.

Degraded mode matrix:

Komponent down	Co nadal działa	Co nie działa
Management plane	Istniejące sesje, auth (cached tokens)	Nowe provisioning, config changes
Session broker	Istniejące sesje	Nowe sesje
G1/G2 (one region)	Sessions w other region (failover)	Sessions w down region
Matrix	Session (non-comms), file transfer	Chat, voice, video
HSM (primary)	Operations z cached keys (limited time)	New key generation, certificate issuance

CDR pipeline	Sessions, communication	File transfer (blocked until CDR back)
Monitoring	All production services	Alerting degraded (backup alerting via email)
SIEM	All production services	Security event analysis delayed

Priority restoration order: 1. HSM / PKI (security foundation). 2. IAM / Authentication (access control). 3. G1/G2 gateways (network connectivity). 4. Session broker (session creation). 5. Matrix (communication). 6. CDR pipeline (file transfer). 7. Management plane (administration). 8. Monitoring / SIEM (observability).

84.9 Disaster communications — escalation, notification

Status: [N] Normatywny Odbiorca: SRE, Account Management, PR, Legal Wpływ na baseline: Wysoki Powiązane rozdziały: 83.7, 84.7, 96.1

Komunikacja podczas katastrofy jest ustrukturyzowana i oparta na szablonach, aby zapewnić szybką i spójną informację.

Internal escalation: | Severity | Powiadamiany | Kanał | Czas | |—|—|—| | P1 | On-call → SRE Lead → CTO → CEO | PagerDuty → Slack → Phone | 5 min → 15 min → 30 min | | P2 | On-call → SRE Lead → Engineering Lead | PagerDuty → Slack | 15 min → 30 min | | Security incident | SOC → CISO → Legal → CEO | SOC bridge → Secure channel | 5 min → 15 min → 30 min | | Data breach | SOC → CISO → Legal → DPO → CEO | Secure channel → Encrypted email | 5 min → 15 min → 1h |

Customer notification: - P1: initial notification w ciągu 15 min od wykrycia. - Template: „[Service] is experiencing [impact]. We are investigating. ETA for update: [time].” - Updates co 30 minut do resolution. - Resolution notification z preliminary cause. - Post-mortem w ciągu 5 dni roboczych.

Regulatory notification: - Data breach (GDPR Art. 33): notification do DPA w ciągu 72h. - Customer notification (GDPR Art. 34): jeśli high risk to individual rights. - Sector-specific notifications (np. BSI dla klientów KRITIS w Niemczech).

84.10 Operational recovery order — component restoration sequence

Status: [N] Normatywny Odbiorca: SRE, DevOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 84.7, 84.8, 97.4

Po pełnym outage, odtwarzanie komponentów odbywa się w ścisłej kolejności uwzględniającej zależności.

Kolejność odtwarzania:

Faza	Komponent	Zależności	Walidacja
0	Network infrastructure (DNS, LB, firewall)	Żadne	Connectivity test
1	HSM (unseal, verify keys)	Network	Key listing, sign test
2	PKI (CA availability, CRL distribution)	HSM, Network	Certificate validation
3	Vault (unseal, secret availability)	HSM, Network	Secret read test
4	IAM / Identity Provider	Vault, PKI, Network	Auth flow test
5	Config store (etcd/Consul)	Network	Config read test
6	Management plane	IAM, Config, Vault	UI login, API response
7	G1/G2 gateways	Network, PKI, Config	IPsec tunnel test
8	Session broker	Config, IAM, G2	Session creation test
9	Workload host (microVM)	Broker, G2, Config	VM start, session attach
10	Matrix core	IAM, PKI, Config	Message send/receive
11	CDR pipeline	Config, Workload	File upload/sanitize test
12	Monitoring / SIEM	Network, Config	Dashboard load, alert test
13	Tenant traffic enablement	All above	E2E session test per tenant

Zasady: - Każda faza wymaga walidacji (smoke test) przed przejściem do następnej. - Jeśli walidacja fazy fails, stop i remediate — nie kontynuować. - Czas na fazę jest dokumentowany (actual vs plan) dla post-mortem. - Runbook dla każdej fazy jest przygotowany i przetestowany (patrz 95.3).

Rozdział 85. Support, eskalacje i operacyjne SLA

85.1 Model supportu — tiered: community → standard → priority → dedicated

Status: [N] Normatywny Odbiorca: Account Management, Support Team, Customers Wpływ na baseline: Średni Powiązane rozdziały: 83.8, 85.2, 85.9

SYLION oferuje cztery poziomy wsparcia, przypisane do tierów usługi.

Tier	Support level	Kanały	Godziny	Response SLA (P1)
STANDARD	Standard	Email, portal	Business hours (CET)	4h
PRO	Priority	Email, portal, phone	Extended (7-22 CET)	1h
STATE	Dedicated	Email, portal, phone, dedicated Slack	24/7	15 min
Community (trial)	Community	Knowledge base, forum	Self-service	Best effort

Standard support: - Ticketing system (Zendesk/JIRA Service Management). - Response SLA per priority: P1 4h, P2 8h, P3 24h, P4 5 dni roboczych. - Resolution SLA: P1 24h, P2 48h, P3 5 dni, P4 30 dni.

Priority support: - Dedicated queue z wyższym priorytetem. - Named support engineers (team, nie osoby dedykowane). - Quarterly business review (QBR) z Account Manager.

Dedicated support: - Dedicated TAM (Technical Account Manager). - Direct access do engineering team (Slack channel per tenant). - Monthly security review. - Custom SLA negotiation (beyond standard tiers). - On-site support dostępny (per agreement).

85.2 L1/L2/L3 definitions and routing

Status: [N] Normatywny Odbiorca: Support Team, Engineering Wpływ na baseline: Średni Powiązane rozdziały: 85.1, 85.3, 85.7

Obsługa zgłoszeń w SYLION jest trójpoziomowa — z jasnym routingiem i kryteriami eskalacji.

L1 — First Contact / Triage: - Klasyfikacja zgłoszenia (priority, component, impact). - Known issue check (knowledge base search). - Basic troubleshooting (standardowe runbook steps). - Zbieranie diagnostyki (logi, screenshots, repro steps). - SLA: resolve lub escalate w ciągu 30 minut (P1) / 2h (P2) / 4h (P3/P4).

L2 — Technical Support: - Deep troubleshooting (log analysis, config review, integration debugging). - Workaround implementation. - Bug confirmation i ticket do engineering. - Access do staging environment dla reprodukcji. - SLA: resolve lub escalate w ciągu 2h (P1) / 8h (P2) / 24h (P3/P4).

L3 — Engineering: - Code-level investigation i fix. - Root cause analysis. - Hotfix development i deployment (via emergency pipeline 80.8). - Architecture-level troubleshooting (sesje z Security/Platform team). - SLA: per incident complexity, but P1 mitigation w ciągu 4h.

Routing: - Automatyczny routing na L1 na podstawie ticket category. - L1 → L2 eskalacja po failed triage lub po 30 min (P1). - L2 → L3 eskalacja po confirming engineering issue lub po 2h (P1). - Security issues: bypass L1, direct to L2 Security Queue.

85.3 Security escalation path — CVSS scoring

Status: [N] Normatywny Odbiorca: Security, Support, SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 83.3, 85.2, 95.1

Zgłoszenia bezpieczeństwa mają dedykowaną ścieżkę eskalacji opartą na CVSS scoring.

CVSS-based routing:

CVSS Score	Severity	Routing	Response
9.0-10.0	Critical	SOC → CISO → Emergency pipeline	Immediate mitigation, hotfix <4h
7.0-8.9	High	SOC → Security Lead → Scheduled fix	Mitigation <24h, fix <7 days
4.0-6.9	Medium	Security Team → Sprint backlog	Fix w następnym sprint/release
0.1-3.9	Low	Security Team → Backlog	Fix w reasonable timeframe

Active exploitation: Jeśli SOC potwierdzi aktywną eksploatację (niezależnie od CVSS): - Auto-escalation do P1. - CISO notified natychmiast. - Immediate mitigation (kill switch, WAF rule, IP block). - Emergency hotfix pipeline activated. - Customer notification per 84.9.

Vulnerability disclosure: - Responsible disclosure program (90-day window). - Dedykowany email security@sylion.io. - Hall of fame dla researchers (za zgodą). - Coordination z CERT jeśli dotyczy supply chain.

85.4 Customer communication model

Status: [N] Normatywny Odbiorca: Support, Operations, Product Management Wpływ na baseline: Wysoki Powiązane rozdziały: 83.7, 84.9, 85.1

Customer communication model definiuje jak i kiedy SYLION komunikuje się z klientami w kontekście operacyjnym.

Kanały komunikacji:

Kanał	Typ	Użycie
Status page (public)	Proactive	Real-time system status, maintenance schedule
Status page (per-tenant)	Proactive	Tenant-specific issues, SLA dashboard
Email notifications	Proactive	Planned maintenance, incident updates, security advisories
In-app notifications	Proactive	Urgent notices for active operators
Support portal (ticket)	Reactive	Ticket updates, resolution communication
Dedicated Slack/Matrix channel	Interactive	STATE tier: real-time communication with operations team
Monthly review meeting	Scheduled	PRO/STATE: SLA review, capacity review, roadmap update

Incident communication SLA:

Severity	First notification	Update frequency	Post-mortem
P1 Critical	<15 min	Co 30 min	Opublikowany w 5 dni roboczych
P2 High	<30 min	Co 1h	Opublikowany w 10 dni roboczych
P3 Medium	<2h	Co 4h (business hours)	Na życzenie
P4 Low	<8h (business hours)	Na zamknięcie	Nie wymagany

Maintenance communication: - Planned maintenance: notification per tier SLA (STATE: 72h, PRO: 48h, STANDARD: 24h) via email + status page. - Emergency maintenance: notification ASAP (target: <15 min from decision to maintain) via all channels. - Maintenance completion: notification within 30 min of completion.

Communication templates: Standardowe templates dla: incident notification, incident update, incident resolution, planned maintenance, emergency maintenance, security advisory, SLA breach notification. Templates zapewniają spójność i kompletność informacji. Reviewed quarterly.

Feedback loop: Post-incident survey do affected tenants (optional, 3 pytania: Was communication timely? Was information sufficient? Overall satisfaction?). Wyniki analizowane monthly, action items per improvement.

85.5 Managed service operations model

Status: [R] Rekomendowany Odbiorca: Operations, Product Management, Sales Wpływ na baseline: Średni Powiązane rozdziały: 85.1, 83.1, 86.6

Managed service operations model definiuje jak SYLION dostarcza platformę jako usługę zarządzaną z różnymi poziomami zarządzania per tier.

Model odpowiedzialności (RACI per tier):

Obszar	STANDARD	PRO	STATE
Infrastructure provisioning	SYLION	SYLION	SYLION
OS/firmware patching	SYLION	SYLION	SYLION
Security monitoring	SYLION (basic)	SYLION (advanced)	SYLION + dedicated SOC
Incident response	SYLION L1-L2	SYLION L1-L3	Dedicated team
Capacity management	SYLION (reactive)	SYLION (proactive)	Dedicated capacity planning
Backup management	SYLION	SYLION	SYLION + tenant verification
DR testing	SYLION (automated)	SYLION (quarterly)	SYLION + tenant participation
Configuration management	Tenant self-service	SYLION + tenant	Dedicated configuration management
Compliance reporting	Tenant self-service	SYLION (basic)	SYLION + dedicated compliance
Custom integrations	Not included	Limited	Full support

Operational touchpoints: 1. Onboarding — tenant provisioning, configuration, training (per 91.7). 2. Day-2 operations — monitoring, alerting, incident response, patching, scaling. 3. Change management — planned changes communicated in advance per tier SLA (STATE: 72h notice, PRO: 48h, STANDARD: 24h). 4. Reviews — monthly ops review (PRO), weekly ops review (STATE), including: SLA performance, incident summary, capacity forecast, upcoming changes.

Staffing model: - STANDARD: shared operations team, ratio 1 engineer

50 tenants. - PRO: shared operations team, ratio 1 engineer : 20 tenants. - STATE: dedicated operations pod (2-3 engineers per tenant cluster), follow-the-sun coverage.

Boundaries: SYLION manages platform. Tenant manages: user accounts (via admin portal), content (E2EE — SYLION has no access), business processes, end-user devices (MDM integration available but managed by tenant).

85.6 On-call model — follow-the-sun for STATE tier

Status: [N] Normatywny Odbiorca: SRE, Engineering Leadership Wpływ na baseline: Wysoki Powiązane rozdziały: 83.4, 85.1, 85.2

Model on-call zapewnia ciągłą dostępność engineering response.

STANDARD/PRO on-call: - Single timezone (CET/CEST) on-call rotation. - Business hours (9-18 CET): full team available. - Off-hours: on-call engineer + secondary backup. - Rotation: 1-week shifts, 4-person minimum pool.

STATE on-call (follow-the-sun): - Multi-timezone rotation (np. CET + UTC + IST). - 24/7 coverage z primary on-call w business hours local timezone. - Handoff procedure: end of shift → briefing do next timezone (15-min call, open incidents listed). - Escalation: primary → secondary → SRE Lead → CTO (per timezone).

On-call expectations: - Response time: P1 alert → acknowledge w 5 min, start investigation w 15 min. - Availability: on-call engineer dostępny w ciągu 15 min (nie musi być przy biurku, ale z laptopem i internet). - Tooling: VPN access, admin credentials (scoped), runbook access. - Compensation: on-call premium + incident premium za after-hours incidents.

85.7 Escalation matrix

Status: [N] Normatywny Odbiorca: SRE, Support, Engineering Leadership Wpływ na baseline: Wysoki Powiązane rozdziały: 83.3, 83.4, 85.2

Macierz eskalacji definiuje automatyczne i manualne ścieżki eskalacji.

Time-based escalation (automatyczna):

Priority	Bez mitigation po	Eskalacja do
P1	15 min	SRE Lead
P1	30 min	Engineering Manager
P1	1h	CTO
P1	2h	CEO
P2	1h	SRE Lead
P2	4h	Engineering Manager
P3	24h	SRE Lead

Functional escalation:

Typ problemu	Primary	First escalation	Final escalation
Infrastructure	SRE	SRE Lead	CTO
Security	SOC	CISO	CEO
Application	Engineering	Engineering Manager	CTO

Customer impact	Support	Account Manager	VP Sales
Data breach	SOC	CISO + DPO	CEO + Legal
Regulatory	Compliance	DPO	CEO + Legal

Customer escalation: Klient STATE tier może eskalować bezpośrednio do TAM. Klient PRO może eskalować przez Account Manager. Klient STANDARD eskaluje przez ticket system.

85.8 Priority definitions — P1-P4 with business impact

Status: [N] Normatywny Odbiorca: Support, SRE, Account Management Wpływ na baseline: Średni Powiązane rozdziały: 83.3, 85.7, 95.1

Definicje priorytetów z perspektywy business impact (uzupełnienie 83.3 o kontekst biznesowy).

Priority	Business impact	Przykłady SYLION
P1	Revenue-impacting, all customers affected, data loss/breach risk	Full outage, region down, active data breach, HSM compromise, >50% sessions failed
P2	Significant degradation, multiple customers affected	Partial outage, one component failed, elevated error rates, security vulnerability with no active exploit
P3	Limited impact, workaround available, single customer affected	One tenant issue, non-critical feature broken, performance degradation <20%
P4	Minimal impact, cosmetic, improvement opportunity	UI glitch, documentation error, minor performance tuning, feature request

Priority override: - Security issues: minimum P2, regardless of customer impact scope. - STATE tier issues: one priority level upgrade vs STANDARD (np. P3 STANDARD → P2 STATE). - Customer escalation: Account Manager może upgrade priority z justification.

85.9 Tenant classes and support tiers

Status: [N] Normatywny Odbiorca: Account Management, Support Wpływ na baseline: Średni Powiązane rozdziały: 82.7, 85.1, 85.8

Klasyfikacja tenantów wpływa na support level, SLA, i communication model.

Tenant class	Tier	Support	SLA	Communication	Pricing
Commercial Small	STANDARD	Standard	99.5% E	mail, portal 4	00€/user/month
Commercial Enterprise	PRO	Priority	99.9% E	mail, portal, 1 phone	500€/user/month
Government / Sovereign	STATE	Dedicated	99.95%+ (custom)	All channels	2500€/user/month (min 50 users)
Trial / Evaluation	Community	Community	Best effort	Knowledge base	Free (limited)

Upgrade path: Tenant może upgrade tier w dowolnym momencie. Downgrade wymaga 30-day notice i migration plan (np. STATE → PRO wymaga przeglądu czy funkcjonalności STATE-only nie są w użyciu).

Custom SLA: STATE tier tenants mogą negocjować custom SLA powyżej standardowego — np. 99.995% availability, dedicated infrastructure, custom RPO/RTO. Custom SLA wymaga engineering review przed zatwierdzeniem.

Rozdział 86. Asset management i lifecycle operacyjny

86.1 Asset registry — all hardware, software, certificates in CMDB

Status: [N] Normatywny Odbiorca: SRE, Security, Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 86.2, 86.5, 86.8

CMDB (Configuration Management Database) SYLION rejestruje wszystkie zasoby — fizyczne, wirtualne i logiczne.

Kategorie zasobów:

Kategoria	Przykłady	Atrybuty
Compute	VPS, microVM images, container images	Region, tier, tenant, OS version, image hash
Network	VPN endpoints, firewalls, DNS zones, load balancers	IP range, protocol, config hash
Storage	Block storage, S3 buckets, backup targets	Region, encryption, retention policy
Software	OS packages, application versions, library versions	Version, SBOM link, CVE status
Certificates	TLS, IPsec, code signing, root CA	CN, expiry, issuer, key algorithm, HSM slot
Keys	Encryption keys, signing keys, API keys	Type, HSM-stored, rotation date, owner
Accounts	Service accounts, admin accounts, tenant accounts	Owner, MFA status, last access, permissions

CMDB as source of truth: CMDB jest automatycznie synchronizowany z infrastructure state (Terraform output, cert-manager status, Vault inventory). Manual entries wymagane wyłącznie dla zasobów fizycznych (HSM appliances, network hardware).

Audytability: Każda zmiana w CMDB jest logowana (kto, kiedy, co zmieniło się). CMDB diff jest dostępny dla audytorów. Quarterly CMDB review: weryfikacja, że inventory matches reality.

86.2 Terminal registry — per-operator terminal tracking

Status: [N] Normatywny Odbiorca: Security, IT Operations Wpływ na baseline: Wysoki Powiązane rozdziały: 86.1, 90.1, 86.9

Każdy terminal operatora (thin client device) jest zarejestrowany w registry z pełnym lifecycle tracking.

Atrybuty terminala: - Device ID (unikatowy, hardware-bound). - Model / hardware revision. - Firmware version (current, last update date). - Assigned operator (user binding). - Assigned tenant. - Compliance status (up-to-date firmware, valid certificate, security baseline met). - Last seen (heartbeat timestamp). - Location (optional, per tenant policy).

Lifecycle: 1. Provisioning: nowy terminal rejestrowany w registry, firmware flashed, certificates issued. 2. Assignment: terminal przypisany do operatora i tenanta. 3. Operation: terminal regularnie raportuje heartbeat z firmware version i compliance status. 4. Maintenance: firmware update pushed, certificate renewed. 5. Reassignment: terminal odłączony od operatora, wiped, reassigned. 6. Decommission: terminal wiped, certificate revoked, removed from registry, physical disposal documented.

Non-compliant terminal: Terminal, który nie spełnia compliance requirements (outdated firmware, expired certificate, missing heartbeat >24h) jest automatycznie blokowany — nie może nawiązać sesji. Alert do administratora tenanta.

86.3 Router registry — firmware version, config hash, last audit

Status: [N] Normatywny Odbiorca: Network Engineering, Security, Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 86.1, 86.4, 90.2
Router registry to centralny rejestr wszystkich routerów/bram sieciowych SYLION, zarządzany jako część CMDB z automatyczną walidacją stanu.

Atrybuty per router:

Atrybut	Opis	Źródło
Router ID	Unikalny identyfikator	Auto-generated
Model/Vendor	Sprzęt, producent	Provisioning
Firmware version	Aktualna wersja firmware	Automated scan
Config hash	SHA-256 hash aktualnej konfiguracji	Automated scan
Expected config hash	Hash oczekiwanej konfiguracji (z IaC)	Config store
Last audit	Data ostatniego audytu	Audit system
Compliance status	Compliant / Non-compliant / Unknown	Automated check
VPN profile	IPsec profile (classical/hybrid PQC/full PQC)	Config store
Certificate expiry	Data wygaśnięcia certyfikatu IPsec	PKI system
Region/Zone	Lokalizacja fizyczna/logiczna	Provisioning
Tenant assignment	Którzy tenanti routowani przez ten router	Session manager

Automatyczna walidacja: - Config drift detection — co 15 min porównanie actual config hash z expected. Drift → alert P2 + investigation. - Firmware compliance — porównanie installed version z approved version list. Outdated firmware → alert P3 + patch schedule. - Certificate monitoring — alert 30 dni przed wygaśnięciem certyfikatu (automated renewal trigger). - Security posture — weryfikacja: kill switch enabled, DNS leak protection, WebRTC blocking, IPsec tunnel health.

Lifecycle events: Każda zmiana w registry logowana: provisioning, firmware update, config change, certificate renewal, audit result, decommissioning. Audit trail immutable (Zone 4).

Integration: Router registry zintegrowany z vulnerability management (firmware CVE matching), change management (planned vs unplanned changes), incident management (router → affected tenants mapping).

86.4 Key and token registry — automated, HSM-linked

Status: [N] Normatywny Odbiorca: Security, PKI Team Wpływ na baseline: Krytyczny Powiązane rozdziały: 75.1, 82.3, 86.5

Rejestr kluczy i tokenów prowadzi inventory wszystkich kluczy kryptograficznych i tokenów w systemie.

Typy kluczy: - HSM master keys (root of trust). - CA signing keys (root CA, intermediate CA). - TLS keys (per-service, per-endpoint). - IPsec keys (per-tunnel). - Code signing keys. - Encryption at rest keys (per-tenant, per-volume). - API tokens (service-to-service). - User session tokens (ephemeral, not in registry — only template tracked).

Registry atrybuty: - Key ID / alias. - Algorithm (RSA-4096, P-384, ML-KEM-1024, ML-DSA-87...). - Storage location (HSM slot, Vault path). - Creation date, rotation date, expiry date. - Owner (service, team). - Usage (signing, encryption, key exchange). - Rotation policy (auto/manual, frequency).

Automation: Registry jest automatycznie synchronizowany z HSM inventory i Vault. Nowy klucz wygenerowany w HSM automatycznie pojawia się w registry. Klucz z approaching expiry automatycznie triggeruje renewal workflow lub alert.

Audit: Quarterly key audit: verify that all keys in registry exist in HSM/Vault, no orphaned keys, no keys past rotation deadline.

86.5 Certificate registry — expiry tracking, automated renewal

Status: [N] Normatywny Odbiorca: Security, SRE, PKI Team Wpływ na baseline: Krytyczny Powiązane rozdziały: 86.1, 86.4, 82.8

Rejestr certyfikatów śledzi wszystkie certyfikaty X.509 w ekosystemie SYLION.

Typy certyfikatów: - Root CA certificate (long-lived, HSM-stored). - Intermediate CA certificates (medium-lived, HSM-stored). - TLS server certificates (per-service, auto-renewed). - TLS client certificates (per-terminal, per-operator). - IPsec certificates (per-gateway). - Code signing certificates. - OCSP responder certificates.

Expiry tracking: - Dashboard z wszystkimi certyfikatami sortowanymi po expiry date. - Alert thresholds: 90 dni (info), 30 dni (warning), 14 dni (critical), 7 dni (P2 alert). - Auto-renewal: cert-manager automatycznie renowuje certyfikaty z ≥30 dni buffer. - Manual renewal: root CA i intermediate CA — ceremonia manualna z key custodians.

Certificate transparency: Dla publicznych certyfikatów TLS: monitorowanie Certificate Transparency logs. Alert jeśli nieznan certyfikat wystawiony dla domeny SYLION.

Revocation: - CRL publication (co 1h refresh). - OCSP responder (real-time revocation check). - Certificate revoked → immediate push do all endpoints consuming it.

86.6 Tenant and environment registry

Status: [N] Normatywny Odbiorca: Platform Engineering, Operations, Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 86.1, 79.6, 83.7

Tenant registry to centralny rejestr wszystkich tenantów SYLION i ich środowisk, stanowiący single source of truth dla operacji, billing i compliance.

Atrybuty per tenant:

Atrybut	Opis
Tenant ID	Unikalny identyfikator (UUID)
Tenant name	Nazwa organizacji
Tier	STANDARD / PRO / STATE
Region (primary)	Region główny (data residency)
Region (DR)	Region DR (jeśli skonfigurowany)
Operator count	Liczba aktywnych operatorów
Contract start/end	Daty kontraktu
SLA profile	Profil SLA per tier
Compliance requirements	GDPR, sector-specific (np. healthcare, defense)
Data residency	Kraj/region wymagany dla danych
Encryption profile	Classical / Hybrid PQC / Full PQC
Support tier	Community / Standard / Priority / Dedicated
Status	Active / Suspended / Decommissioning / Archived

Atrybuty per environment (per tenant):

Atrybut	Opis
Environment ID	UUID
Type	Production / Staging / DR
Cluster	Kubernetes cluster assignment
Resource allocation	CPU, RAM, storage quotas
Network isolation	Namespace, NetworkPolicy, VLAN
Last health check	Timestamp + status

Governance: - Tenant creation wymaga approval (commercial + technical review). - Tier change wymaga migration plan (79.6) i approval. - Decommissioning wymaga data destruction plan i evidence (86.9). - Registry changes audited — immutable log w Zone 4.

Automatyzacja: - Health dashboard per tenant (83.7) automatycznie generowany z registry. - SLA reporting (83.8) korzysta z registry dla tier/SLA mapping. - Billing integration — operator count × tier rate × add-ons. - Compliance reporting — automatyczny raport per tenant z compliance requirements status.

86.7 Asset lifecycle — provisioning → operation → decommission

Status: [N] Normatywny Odbiorca: Operations, Security, Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 86.1, 86.9, 79.4

Każdy asset w SYLION przechodzi zdefiniowany lifecycle z jasnymi stanami, przejściami i wymaganiami per etap.

Stany lifecycle:

[Planned] → [Provisioning] → [Active] → [Maintenance] → [Decommissioning] → [Destroyed/Archived] ↑ ↓ ← —————→

Provisioning: - Asset request (automated via IaC lub manual via ticket). - Approval (per asset type: auto for standard VMs, manual for HSM/hardware). - Provisioning execution (Terraform/Pulumi/Ansible). - Configuration injection (per role, per tenant, per environment). - Security baseline application (hardening, certificates, policies). - Validation (health check, security scan, compliance check). - Registration in CMDB with all attributes. - Status → Active.

Active (operation): - Continuous monitoring (health, performance, security). - Patching and updates (per maintenance policy). - Configuration management (drift detection, compliance checks). - Certificate renewal (automated). - Capacity review (monthly). - Audit (per schedule: quarterly for critical, annually for standard).

Maintenance: - Planned downtime (per tier SLA maintenance windows — 79.8). - Firmware/OS updates. - Hardware replacement (for physical assets). - Capacity scaling. - Status returns to Active after maintenance.

Decommissioning (szczegóły w 86.9): - Trigger: end of life, replacement, tenant offboarding, security incident. - Data migration or destruction. - Certificate revocation. - DNS/routing removal. - Resource release. - Evidence of destruction. - Status → Destroyed/Archived.

Tracking: Każde przejście między stanami logowane z: timestamp, initiator (person/automation), reason, approval (jeśli wymagane). Asset bez zmiany stanu >12 miesięcy → automatic review trigger.

Metryki: - Mean time from Planned to Active (provisioning efficiency). - % assets in each lifecycle state. - Mean time in Decommissioning (target: <30 dni). - % assets with overdue audit.

86.8 Disposal and decommissioning — data destruction evidence

Status: [N] Normatywny Odbiorca: Security, Compliance, SRE Wpływ na baseline: Wysoki Powiązane rozdziały: 86.7, 86.9, 84.2

Decommissioning zasobów SYLION obejmuje bezpieczne usunięcie danych i kryptomateriału.

Cloud resources: 1. Backup (jeśli applicable) → verify backup integrity. 2. Data wipe: overwrite storage (cryptographic erase preferowane — usunięcie encryption key). 3. Resource deletion z cloud provider. 4. Verification: confirm resource no longer accessible. 5. CMDB update: status = decommissioned, date, method.

Hardware (HSM appliances, terminals, routers): 1. Factory reset / secure erase. 2. Certificate revocation. 3. Physical destruction (shredding) lub return to vendor z documented chain of custody. 4. Evidence of destruction: photograph, serial number, date, witness.

Certificates and keys: 1. Certificate revoked (CRL + OCSP update). 2. Key destroyed in HSM (zeroize command). 3. HSM audit log confirming key destruction. 4. CMDB update.

Timing: - Decommissioned assets: data wiped w ciągu 24h od decommission decision. - Revoked certificates: published w ciągu 1h (CRL refresh cycle). - Physical disposal: w ciągu 30 dni od decommission.

86.9 Evidence of destruction/retirement

Status: [N] Normatywny Odbiorca: Compliance, Security, Audit Wpływ na baseline: Wysoki Powiązane rozdziały: 86.7, 86.8, 93.1

Każdy decommissioning generuje evidence package — dokumentację potwierdzającą prawidłowe usunięcie.

Evidence package zawiera: - Asset ID, type, serial number. - Decommission request (ticket reference, authorized by). - Data wipe method (cryptographic erase, overwrite, physical destruction). - Timestamp of destruction. - Certificate revocation confirmation (CRL entry, OCSP response). - HSM key destruction log. - Photographs (hardware destruction). - Witness signature (for physical destruction). - CMDB update confirmation.

Storage: Evidence packages przechowywane w Zone 4 (immutable audit storage) przez minimum 10 lat. Dostępne dla audytorów na żądanie.

Compliance mapping: - ISO 27001 A.11.2.7 (Secure disposal or reuse of equipment). - GDPR Art. 17 (Right to erasure — evidence that data was deleted). - BSI IT-Grundschutz (media disposal requirements).

CZĘŚĆ X — TESTY, WALIDACJA I AKCEPTACJA

Rozdział 87. Strategia testów end-to-end

87.1 E2E scope — zakres testów end-to-end

Status: [N] Normatywny Odbiorca: QA, DevOps, Security Wpływ na baseline: Krytyczny Powiązane rozdziały: 81.3, 88.1, 92.1

Testy end-to-end (E2E) w SYLION weryfikują kompletne ścieżki użytkownika od terminala operatora, przez wszystkie warstwy platformy, aż do workloadu i powrotu.

Zakres E2E: Testy E2E obejmują pełny stos: - Terminal (thin client) → G1 gateway → IPsec tunnel → G2 gateway → session broker → microVM workload → Matrix (komunikacja) → CDR (pliki) → management plane (administracja). - Każdy test E2E przechodzi przez wszystkie zone'y bezpieczeństwa (Zone 0 → Zone 1 → Zone 2 → Zone 3 → Zone 4 telemetry).

Scope definicja: - Operator journey: kompletna ścieżka operatora od logowania do wylogowania, z wszystkimi typami interakcji (sesja, komunikacja, pliki). - Admin journey: kompletna ścieżka administratora (provisioning, config change, monitoring review). - Degraded mode: zachowanie systemu gdy komponent jest niedostępny. - Failover: automatyczne przełączenie na secondary region/node. - Recovery: odtworzenie po awarii. - Interoperability: współpraca z zewnętrznymi systemami (SSO IdP, SIEM, custom integrations).

Środowisko: Testy E2E wykonywane w dedykowanym E2E environment, który jest full replica produkcji (te same wersje, konfiguracja, policies), ale z synthetic tenants i synthetic users.

Częstotliwość: - Przed każdym deploy do production (blocking gate). - Nightly full regression E2E suite. - Weekly extended E2E (degraded mode + failover scenarios).

87.2 Operator journey tests

Status: [N] Normatywny Odbiorca: QA, Product Wpływ na baseline: Krytyczny Powiązane rozdziały: 81.3, 87.1, 89.1

Testy operator journey weryfikują kompletne ścieżki operatora w systemie.

Scenariusze:

Fresh login + session:

Operator uruchamia terminal → łączy się przez G1 → autentykuje (MFA) → broker przydziela sesję → microVM startuje → operator pracuje w workload → wylogowuje się → sesja zamknięta, microVM destroyed.

Communication:

Operator w sesji → inicjuje chat z innym operatorem → wysyła wiadomość → odbiorca otrzymuje → odpowiedź → voice call → video call → zakończenie.

File transfer:

Operator uploaduje plik → CDR sanitization → plik dostępny w workspace → operator downloaduje plik z innego operatora → CDR weryfikacja.

Multi-device:

Operator loguje się na drugim terminalu → sesje na obu terminalach → przełączanie między terminalami.

Offline/reconnect:

Operator traci połączenie → reconnect automatyczny → sesja kontynuowana → brak utraty stanu.

Metryki per scenariusz: - Success rate (100% required for pass). - Duration (per step i total, porównanie z baseline). - Error count (0 expected). - Resource consumption (VM CPU/RAM during test).

87.3 Admin journey tests

Status: [N] Normatywny Odbiorca: QA, Platform Engineering, Product Wpływ na baseline: Wysoki Powiązane rozdziały: 87.1, 87.2, 91.1

Admin journey tests weryfikują kompletne scenariusze administracyjne z perspektywy administratora SYLION.

Testowane journey:

Tenant management journey: 1. Create new tenant → configure tier → assign region → provision environment → verify health → invite first admin → admin login → configure tenant settings → add first operator → verify operator access.

Operator lifecycle journey: 2. Create operator account → assign role → provision terminal → assign workload profile → operator first login → session creation → verify E2E connectivity → modify operator permissions → verify permission change effective → deactivate operator → verify access revoked.

Security administration journey: 3. Configure security policy → deploy policy → verify enforcement → modify policy → verify update propagated → review audit logs → export compliance report.

PKI management journey: 4. Request certificate → approve request → issue certificate (HSM signing) → deploy certificate → verify TLS/IKEv2 using new cert → schedule rotation → execute rotation → verify continuity → revoke old certificate.

Monitoring administration journey: 5. Configure alert rules → trigger test alert → verify notification delivery → acknowledge alert → follow runbook → resolve → verify alert closure → review dashboard.

Disaster recovery journey: 6. Trigger DR test → verify failover → verify data consistency → verify session recovery → fallback → verify normal operation restored.

Kryteria pass/fail: - Każdy step w journey musi zakończyć się sukcesem. - Czas każdego step mierzony — regression jeśli >20% wolniej niż baseline. - Security assertions per step: unauthorized user cannot execute step, audit log entry created per step, no data leakage between tenants. - Journey test failure = deployment

blocker (quality gate per 92.7).

Automatyzacja: Admin journey tests w pełni zautomatyzowane (Playwright/Cypress dla UI, API calls dla backend). Uruchamiane: daily w staging, pre-deployment w pipeline, weekly w production-like environment.

87.4 Degraded mode tests

Status: [N] Normatywny Odbiorca: QA, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 84.8, 87.1, 97.1

Testy degraded mode weryfikują zachowanie systemu, gdy jeden lub więcej komponentów jest niedostępny.

Scenariusze:

Session broker down: istniejące sesje kontynuują, nowe sesje blokowane, alert wygenerowany.

Matrix down: sesje operacyjne (non-comms) kontynuują, chat/voice/video niedostępne, alert wygenerowany.

CDR pipeline down: sesje kontynuują, file transfer blokowany, alert wygenerowany.

Management plane down: istniejące sesje kontynuują (cached auth), admin operations blokowane.

HSM down (primary): operacje z cached keys kontynuują (limited time), new key operations blokowane, failover do secondary HSM.

Monitoring down: production kontynuuje, alerting degraded, backup alerting (email) aktywny.

Single G2 node down: traffic automatycznie przełączony na other G2 nodes.

Validation: Każdy degraded mode test weryfikuje: - Graceful degradation (no crash, no data loss). - Proper alerting (correct severity, correct routing). - Documented behavior matches actual behavior (per 84.8 matrix). - Recovery after component restoration (automatic, no manual intervention).

87.5 Failover tests

Status: [N] Normatywny Odbiorca: QA, SRE, Architecture Wpływ na baseline: Krytyczny Powiązane rozdziały: 79.5, 84.5, 97.2

Failover tests weryfikują, że system SYLION prawidłowo przełącza się na zasoby zapasowe przy awarii komponentów lub regionów.

Scenariusze failover:

Component-level failover: 1. Broker failure — kill jednego session brokera → verify sessions reallocated to healthy brokers → verify user interruption <10s → verify broker auto-rebuilt (97.3). 2. Gateway (G1/G2) failure — kill jednego gateway → verify traffic rerouted → verify no session loss → verify gateway auto-rebuilt. 3. Database replica failure — kill jednej repliki → verify reads served by remaining replicas → verify write availability → verify replica auto-rebuilt i synced. 4. HSM failover — simulate HSM unresponsive → verify operations routed to backup HSM → verify no signing delay >5s. 5. Matrix server failure — kill jednego Synapse worker → verify message delivery continues → verify state resolution correct after recovery.

Region-level failover: 6. Full region failure — simulate region outage (all components) → verify DNS failover to secondary region → verify session recreation in secondary → verify data consistency (RPO check) → verify failover time within SLA (per 84.3). 7. Partial region degradation — simulate 50% packet loss in primary region → verify automatic traffic rerouting → verify session quality maintenance.

Network failover: 8. ISP failover — simulate primary ISP outage → verify BGP failover to secondary ISP → verify no session interruption. 9. VPN tunnel failure — simulate IPsec tunnel drop → verify automatic re-establishment → verify session continuity via IKEv2 rekey.

Metryki per test: - Failover detection time (target per 97.2 SLA). - Failover execution time. - Data loss (should be within RPO per 84.3). - User-perceived interruption duration. - Post-failover system health (all health checks passing).

Frequency: Component failover: monthly w staging, quarterly w production (controlled). Region failover: quarterly w staging, semi-annually w production (per 84.7). Results documented i reviewed w DR exercise report.

87.6 Recovery tests

Status: [N] Normatywny Odbiorca: QA, SRE, Operations Wpływ na baseline: Krytyczny Powiązane rozdziały: 84.5, 84.10, 87.5

Recovery tests weryfikują zdolność systemu do pełnego powrotu do normalnego stanu po awarii, łącznie z przywróceniem danych i operacji.

Scenariusze recovery:

Backup restore: 1. Config restore — przywrócenie konfiguracji z backupu → verify all components configured correctly → verify no drift from backup state. 2. IAM state restore — przywrócenie IAM (users, roles, policies) z backupu → verify all users can authenticate → verify permissions correct. 3. PKI restore — przywrócenie PKI state (non-secret) → verify certificate chain valid → verify new certificates can be issued. 4. Telemetry restore — przywrócenie logów i metryk z backupu → verify forensic query capability → verify data completeness.

Full disaster recovery: 5. Single region rebuild — starting from scratch in new region using backups and IaC → verify full system operational → verify data consistency within RPO → measure total RTO. 6. Multi-region recovery — primary i secondary region lost → recover from offline backups → measure RTO for catastrophic scenario.

Partial recovery: 7. Single component recovery — przywrócenie jednego komponentu po corruption → verify no cascading effects → verify integration with other components. 8. Tenant recovery — przywrócenie danych jednego tenanta bez wpływu na pozostałych → verify tenant isolation maintained during restore.

Operational recovery order testing (per 84.10): 9. Weryfikacja sekwencji recovery: HSM/PKI → IAM → Network/VPN → Matrix → Brokers → Workloads → Monitoring → verify each layer operational before proceeding to next.

Metryki: - RTO achieved vs SLA target (per tier per 84.3). - RPO achieved vs SLA target. - Data integrity post-recovery (checksum verification). - System health post-recovery (all health checks passing within 15 min). - Operator productivity post-recovery (sessions working, communication flowing).

Frequency: Automated restore testing weekly (per 84.5). Full DR exercise quarterly w staging, annually w production-like environment.

87.7 Interoperability tests

Status: [R] Rekomendowany Odbiorca: QA, Architecture, Integration Engineering Wpływ na baseline: Średni Powiązane rozdziały: 74.8, 88.7, 78.3

Interoperability tests weryfikują zdolność SYLION do współpracy z zewnętrznymi systemami, standardami i implementacjami.

Zakres testów:

Protocol interoperability: 1. IKEv2 — interoperability z major VPN implementations (strongSwan, Cisco, Palo Alto, Fortinet). Test: tunnel establishment, rekey, DPD, fragmentation. PQC hybrid: interop z implementacjami RFC 9370. 2. TLS 1.3 — interoperability z major TLS libraries (OpenSSL, BoringSSL, GnuTLS, wolfSSL). Test: handshake, resumption, 0-RTT, hybrid PQC key exchange. 3. Matrix protocol — interoperability z Matrix reference implementation (Synapse), alternative implementations (Dendrite, Conduit). Test: federation, E2EE (Megolm/Olm), state resolution. 4. SAML/OIDC — interoperability z major IdPs (Azure AD/Entra ID, Okta, Keycloak, Google Workspace). Test: authentication flow, token exchange, attribute mapping.

Integration interoperability: 5. SIEM — export do major SIEM platforms (Splunk, QRadar, Sentinel, Elastic). Test: event format, transport (Syslog, HTTPS, Kafka), field mapping. 6. HSM — interoperability z major HSM vendors (Thales Luna, Utimaco, Entrust nShield, AWS CloudHSM). Test: PKCS#11, key generation, signing, PQC operations. 7. MDM — interoperability z MDM solutions (Intune, JAMF, VMware Workspace ONE). Test: device enrollment, compliance reporting, policy enforcement.

Standards compliance: 8. FIPS 203/204/205 — PQC algorithm compliance tests (NIST test vectors). 9. X.509v3 — certificate format compliance, hybrid certificate format. 10. OpenTelemetry — telemetry export compliance with OTLP standard.

Matrix testów: Każdy test case: setup → execute → validate → document. Wyniki: compatible / partially compatible (z workaround) / incompatible. Incompatibility → bug report lub known limitation documentation.

Frequency: Pełna matryca interoperability testowana per major release. Subset (critical paths) testowany per minor release. Nowa integracja wymaga pełnego interoperability test przed GA.

Rozdział 88. Testy integracyjne i kontraktowe

88.1 Matrix ↔ IAM

Status: [N] Normatywny Odbiorca: Developers, QA, Security Wpływ na baseline: Krytyczny Powiązane rozdziały: 81.1, 88.8, 90.1

Integracja Matrix ↔ IAM jest krytyczna — kontroluje dostęp operatorów do komunikacji i zapewnia, że stan autoryzacji jest spójny.

Testowane interakcje:

User provisioning: 1. IAM tworzy użytkownika → Matrix account created → verify Matrix user can join rooms → verify displayname/metadata synced. 2. IAM deaktywuje użytkownika → Matrix sessions terminated → verify user cannot send/receive messages → verify historical messages retained per retention policy. 3. IAM zmienia rolę użytkownika → Matrix power levels updated → verify room permissions reflect new role.

Authentication flow: 4. Operator authenticates via IAM (OIDC) → receives Matrix access token → verify token valid for Matrix operations → verify token expiry enforced. 5. Token refresh — IAM issues new token → Matrix accepts new token → old token invalidated. 6. Failed authentication — invalid credentials → Matrix access denied → verify no partial access.

Authorization enforcement: 7. Room creation — only users with admin role in IAM can create rooms → verify enforcement. 8. Room join — only users in tenant's IAM can join tenant's rooms → verify cross-tenant isolation. 9. Message sending — verify only active, authenticated users can send → verify deactivated user cannot send even with cached token.

Edge cases: 10. IAM unavailable — Matrix continues with cached tokens (grace period configurable: 5-15 min) → after grace period, sessions terminated → IAM recovery → sessions restorable. 11. Concurrent IAM changes — bulk user deactivation → verify all Matrix sessions terminated within 60s. 12. Clock skew — IAM and Matrix server clocks out of sync by >5s → verify token validation handles gracefully.

Contract: Consumer: Matrix (expects IAM API for user validation, token verification). Provider: IAM (provides authentication, authorization, user lifecycle API). Contract versioned, tested per 81.1.

88.2 G2 ↔ policy engine

Status: [N] Normatywny Odbiorca: Developers, QA, Security Wpływ na baseline: Krytyczny Powiązane rozdziały: 88.1, 92.4, 90.3

G2 gateway konsultuje policy engine (OPA) przy każdej decyzji o dostępie — integracja musi być niezawodna i szybka.

Testowane interakcje:

Access decision flow: 1. Operator request → G2 constructs policy query (user, resource, action, context) → policy engine evaluates → allow/deny returned → G2 enforces. 2. Policy evaluation latency — P99 <10ms (w ramach G2 processing budget). Testy pod load: 1000 concurrent policy evaluations. 3. Policy engine unavailable — G2 zachowanie per configuration: fail-closed (deny all — default for STATE tier) lub fail-open z reduced functionality (configurable for STANDARD/PRO).

Policy update propagation: 4. New policy deployed → verify propagation to all policy engine instances <30s. 5. Policy rollback → verify old policy restored and enforced <30s. 6. Conflicting policies — verify resolution strategy (most restrictive wins for security policies).

Context enrichment: 7. G2 provides full context: user identity, device attestation, network location, time, session metadata → policy engine uses all dimensions. 8. Missing context — jeśli G2 nie może dostarczyć required context (e.g., device attestation unavailable) → policy engine denies (fail-closed for missing security context).

Tenant isolation: 9. Policy evaluation dla tenant A nie może odwoływać się do danych/polityk tenant B → verify isolation. 10. Shared policies (platform-wide) vs tenant-specific policies → verify precedence (platform policy cannot be overridden by tenant to weaken security).

Performance under load: 11. Burst: 10,000 policy evaluations in 1s → verify no evaluation dropped, latency P99 <50ms. 12. Large policy set: 1000 rules per tenant → verify evaluation time still within budget.

Failure modes: 13. Policy engine crash mid-evaluation → G2 retries (1x) → if still failed, fail-closed. 14. Policy engine returns invalid response → G2 treats as deny + alert.

88.3 G2 ↔ staging (workload provisioning)

Status: [N] Normatywny Odbiorca: Developers, QA, Platform Engineering Wpływ na baseline: Wysoki Powiązane rozdziały: 88.4, 79.4, 97.4

G2 zarządza provisioningiem workloadów (microVM) na żądanie operatora — integracja z warstwą staging/provisioning musi być niezawodna.

Testowane interakcje:

Workload provisioning flow: 1. Operator request → G2 validates (policy check per 88.2) → G2 sends provisioning request to staging layer → staging provisions microVM (Firecracker) → microVM boots → health check passes → G2 receives ready notification → operator session connected. 2. End-to-end provisioning time: <5s (Firecracker boot <1s + config injection + health check). 3. Provisioning failure — staging cannot provision (resource exhaustion) → G2 receives error → G2 retries on different node → if all retries fail, operator receives clear error message.

Workload lifecycle: 4. Session end → G2 notifies staging → staging terminates microVM → resources released → verify no orphaned VMs. 5. Workload health check failure → staging notifies G2 → G2 initiates session reallocation (per 97.2) → new workload provisioned → operator reconnected. 6. Scheduled workload refresh (STATE tier daily rebuild) → staging provisions new → G2 migrates session → old workload destroyed.

Resource management: 7. Resource quota enforcement — G2 tracks per-tenant resource usage → staging refuses provisioning if quota exceeded → G2 returns quota error to operator/admin. 8. Resource reservation — STATE tier pre-allocated resources → verify provisioning from reserved pool (guaranteed capacity). 9. Auto-scaling trigger — staging signals G2 about capacity thresholds → G2 adjusts admission control.

Security integration: 10. TEE attestation — staging provides attestation report for new microVM → G2 verifies attestation → if invalid, microVM destroyed, alert raised. 11. Image integrity — staging verifies microVM image signature before boot → if invalid, provisioning refused. 12. Network isolation — staging configures network namespace/VLAN per tenant → G2 verifies isolation before connecting operator.

Failure modes: 13. Staging layer unavailable → G2 queues requests (bounded queue, 30s timeout) → if staging recovers, queued requests processed → if timeout, operator receives error. 14. Partial staging failure (some nodes down) → G2 routes provisioning to healthy nodes → verify transparent for operator.

88.4 Session broker ↔ workload

Status: [N] Normatywny Odbiorca: Developers, QA, SRE Wpływ na baseline: Krytyczny Powiązane rozdziały: 88.3, 97.2, 89.3

Session broker zarządza mapowaniem sesji operatorów na workloady — integracja krytyczna dla ciągłości pracy.

Testowane interakcje:

Session assignment: 1. New session request → broker selects optimal workload (based on: capacity, proximity, tenant affinity, load) → session assigned → operator connected → verify end-to-end latency. 2. Session affinity — operator reconnects after brief disconnect (<30s) → broker routes to same workload → session state preserved. 3. Load balancing — 100 concurrent session requests → verify even distribution across available workloads (±15% variance).

Session lifecycle: 4. Session heartbeat — broker receives heartbeat from workload co 10s → missing heartbeat → broker marks workload unhealthy after 3 misses → session reallocation triggered. 5. Session termination — operator ends session → broker notifies workload → workload cleanup → resources released → broker updates session registry. 6. Idle session timeout — no operator activity for configurable period (default 30 min) → broker terminates session → workload freed.

Session migration (per 97.2): 7. Broker failure → sessions on failed broker reassigned to healthy brokers → verify session state transferred → verify user interruption <10s. 8. Workload failure → broker assigns session to new workload → verify session state restored (clipboard, display state). 9. Planned migration — drain sessions from broker for maintenance → gradual migration, zero user interruption.

Scaling: 10. Broker reports capacity metrics → management plane scales workload pool → verify new workloads registered with broker → verify broker includes new workloads in assignment. 11. Workload pool shrink — decommission excess workloads → broker drains sessions first → verify graceful removal.

Health monitoring: 12. Broker exposes per-session metrics: latency, throughput, error rate → verify metrics accurate → verify alerting on anomalies. 13. Workload reports resource metrics to broker: CPU, memory, disk → broker uses for assignment decisions.

Failure modes: 14. All workloads in region unhealthy → broker refuses new sessions with capacity error → triggers cross-region failover if configured. 15. Broker ↔ workload network partition → broker cannot verify health → fail-safe: broker attempts reallocation after timeout.

88.5 HSM ↔ PKI

Status: [N] Normatywny Odbiorca: Security, PKI Engineering, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 75.1, 75.3, 78.5

HSM jest hardware trust anchor dla PKI — integracja musi być bezawaryjna, audytowalna i quantum-safe ready.

Testowane interakcje:

Key operations: 1. Key generation — PKI requests new key pair (RSA-4096, ECDSA P-384, ML-DSA-65) → HSM generates → verify key never leaves HSM in plaintext → verify key metadata registered in PKI. 2. Certificate signing — PKI submits CSR → HSM signs with CA key → PKI receives signed certificate → verify signature valid → verify certificate chain complete. 3. Key rotation — PKI requests new key → HSM generates → old key marked for decommission (not destroyed until all certificates using it expired or revoked) → verify seamless transition.

PQC operations: 4. ML-KEM key encapsulation — PKI/transport layer requests KEM operation → HSM performs encapsulation/decapsulation → verify interoperability with liboqs/OpenSSL. 5. ML-DSA signing — PKI requests PQC signature → HSM signs → verify signature with PQC verification library → verify performance within latency budget. 6. Hybrid certificate — HSM signs certificate with both classical (ECDSA) and PQC (ML-DSA) signatures → verify both signatures valid → verify backward compatibility.

Availability: 7. Primary HSM failure → PKI failover to secondary HSM → verify operations continue → verify no signing delay >5s. 8. HSM maintenance — rolling HSM update → verify PKI operations uninterrupted during maintenance. 9. HSM partition isolation — multiple tenants sharing HSM → verify tenant A cannot access tenant B's keys.

Audit and compliance: 10. All HSM operations logged (tamper-evident HSM audit log) → verify logs match PKI operation records → verify no unauthorized key operations. 11. Key ceremony — multi-person authorization for root CA key operations → verify HSM enforces quorum (M of N). 12. FIPS 140-3 validation — verify HSM in FIPS mode → verify only FIPS-approved algorithms available.

Performance: 13. Signing throughput: >100 operations/s (STANDARD), >500/s (PRO), >1000/s (STATE) → verify under load. 14. Key generation time: <1s for RSA-4096, <500ms for ML-DSA-65 → verify benchmarks.

88.6 SIEM ↔ telemetry

Status: [N] Normatywny Odbiorca: Security, SOC, SRE Wpływ na baseline: Wysoki Powiązane rozdziały: 93.5, 94.1, 87.7

Integracja telemetry → SIEM zapewnia, że zdarzenia bezpieczeństwa docierają do SOC w real-time z pełnym kontekstem.

Testowane interakcje:

Event delivery: 1. Security event generated → telemetry collector receives → forwards to SIEM → verify event appears in SIEM <30s od generacji. 2. Bulk events — 10,000 events/s burst → verify no event loss → verify SIEM ingestion keeps up → verify backpressure handling (buffer, not drop). 3. Event format — verify events conform to defined schema (CEF, JSON, OCSF) → SIEM parser correctly extracts all fields.

Event enrichment: 4. Raw event → telemetry enriches with: source component, tenant ID, correlation ID, severity, timestamp (UTC) → SIEM receives enriched event → verify all fields populated. 5. Geo-enrichment — IP addresses enriched with geolocation → verify accuracy. 6. Threat intelligence enrichment — IoC matching → verify matches flagged.

Filtering and sampling: 7. Security events: 100% delivery (no sampling per 94.1) → verify completeness. 8. Performance events: sampling applied → verify SIEM receives sampled subset → verify sampling metadata included. 9. Tenant filtering — SIEM for tenant A receives only tenant A events → verify no cross-tenant event leakage.

Transport reliability: 10. SIEM unavailable → telemetry buffers events (configurable buffer: 1h) → SIEM recovers → buffered events delivered → verify no data loss. 11. Network partition → TLS reconnection with retry → verify events delivered after reconnection. 12. Certificate rotation → SIEM TLS certificate rotated → telemetry reconnects with new cert → verify no event loss during rotation.

Alerting integration: 13. SIEM generates alert based on correlation rule → verify alert correct → verify alert reaches SOC notification channel <60s. 14. SIEM alert contains: source events (linked), severity, recommended action, runbook link.

Compliance: 15. Event retention in SIEM matches Zone 4 retention policy → verify consistency. 16. Event integrity — hash chain from source to SIEM verifiable → tamper detection.

88.7 External integrations

Status: [R] Rekomendowany Odbiorca: Integration Engineering, QA, Partners Wpływ na baseline: Średni Powiązane rozdziały: 74.8, 87.7, 88.8

External integrations obejmują interfejsy SYLION z systemami trzecimi, poza kontrolą SYLION.

Testowane integracje:

Identity Provider (IdP): 1. SAML SSO — login flow z external IdP (Azure AD, Okta, Keycloak) → verify authentication → verify attribute mapping (roles, groups) → verify logout propagation. 2. OIDC — token exchange, refresh, verification → verify with multiple IdPs → verify token revocation handling. 3. SCIM provisioning — user sync from external directory → verify create/update/deactivate propagation.

SIEM export (see also 88.6): 4. Splunk HEC → verify event delivery, field mapping, index assignment. 5. Elastic/OpenSearch → verify Filebeat/Logstash compatibility. 6. Azure Sentinel → verify data connector, schema mapping.

MDM: 7. Device compliance check — MDM reports device compliance → SYLION G2 verifies before session → verify non-compliant device blocked. 8. Certificate deployment — MDM deploys client certificate → SYLION accepts for mTLS → verify end-to-end.

External API consumers: 9. Tenant admin API — third-party management tools consuming SYLION API → verify authentication (API key + mTLS), authorization (scope-limited), rate limiting. 10. Reporting API — external BI tools querying SYLION metrics → verify data correctness, freshness, access control.

Partner integrations: 11. CDR (Content Disarm & Reconstruction) — file upload → CDR processing → sanitized file → verify threat removal → verify document fidelity. 12. Threat intelligence feeds — ingest IoCs → verify matching in traffic/events → verify alert generation.

Testing approach: - Mock-based testing w CI/CD (mock external systems). - Integration environment z real external systems (testowe instancje IdP, SIEM, MDM) — weekly scheduled tests. - Contract testing (88.8) per external API. - Canary monitoring — continuous synthetic checks against production external integrations.

88.8 Contract drift detection

Status: [R] Rekomendowany Odbiorca: Developers, QA, Architecture Wpływ na baseline: Wysoki Powiązane rozdziały: 81.1, 82.8, 88.1

Contract drift detection wykrywa sytuacje, gdy implementacja API rozmiąja się z zdefiniowanym kontraktem, zanim drift dotrze do produkcji.

Mechanizmy detekcji:

Schema drift: 1. OpenAPI spec w repo vs actual API response → automated comparison (tool: Optic, Spectral, custom) → drift detected = PR blocked. 2. gRPC proto definition vs implementation → protobuf lint + integration test → breaking change = CI fail. 3. Matrix protocol compliance → federation test suite → protocol drift = flagged.

Behavioral drift: 4. Contract test (Pact) → consumer expectation vs provider behavior → mismatch = drift → provider must fix or consumer must update expectation. 5. Performance contract — API latency SLO (e.g., P99 <200ms) → measured in integration test → regression = drift. 6. Error contract — expected error

codes/messages vs actual → mismatch = drift.

Configuration drift (cross-reference 82.8): 7. Deployed config vs config store → hash comparison → drift = alert + auto-rollback (per 97.6). 8. Policy drift — deployed OPA policies vs policy repo → drift = alert + investigation.

Detection cadence:

Type	Cadence	Action on drift
Schema drift	Every PR (CI)	Block merge
Behavioral drift	Every deploy (pipeline)	Block deploy
Performance drift	Daily (scheduled)	Alert + investigation
Config drift	Every 5 min (continuous)	Auto-rollback or alert
Policy drift	Every 15 min (continuous)	Alert + investigation

Drift resolution process: 1. Drift detected → alert to owning team. 2. Triage: intentional change (contract update needed) or bug (fix implementation). 3. If intentional: update contract, get consumer approval, update tests. 4. If bug: fix implementation, verify contract still met, deploy fix. 5. Drift unresolved >24h → escalation to Architecture Board.

Metryki: - Drift detection rate (how many drifts found before production). - Mean time to resolve drift. - Drifts reaching production (target: 0).

Rozdział 89. Testy wydajnościowe i skalowalności

89.1 Throughput — przepustowość

Status: [N] Normatywny Odbiorca: QA, SRE, Platform Engineering Wpływ na baseline: Wysoki Powiązane rozdziały: 83.1, 89.2, 89.9

Testy throughput mierzą maksymalną przepustowość systemu w stabilnych warunkach.

Metryki: - Requests per second (management plane API). - Sessions per minute (session creation rate). - Messages per second (Matrix). - Files per minute (CDR pipeline throughput). - Bytes per second (data transfer through G1/G2).

Targets: | Komponent | Target throughput | Measurement condition | | Management API | ≥ 500 req/s | Mixed read/write workload | | Session creation | ≥ 10 sessions/s per broker node | Standard workload profile | | Matrix messaging | ≥ 1000 msg/s per federation | Mixed room sizes | | CDR processing | ≥ 50 files/min per CDR node | Mixed file sizes (1KB-100MB) | | G2 data transfer | ≥ 1 Gbps aggregate per G2 node | Bulk transfer |

Test procedure: Ramping load test: 10% → 25% → 50% → 75% → 100% → 120% of target. At each level: measure throughput, latency, error rate, resource utilization. Identify breaking point.

89.2 Concurrency — współbieżność

Status: [N] Normatywny Odbiorca: QA, SRE, Performance Engineering Wpływ na baseline: Wysoki Powiązane rozdziały: 89.1, 89.3, 83.1

Testy współbieżności weryfikują zachowanie systemu przy dużej liczbie jednoczesnych operacji, wykrywając race conditions, deadlocki i degradację.

Scenariusze:

Connection concurrency: 1. 1000 jednoczesnych połączeń VPN (IKEv2) → verify all tunnels established → measure handshake time distribution → verify no handshake failure. 2. PQc hybrid handshake concurrency — 500 jednoczesnych hybrid handshakes → verify ML-KEM overhead nie powoduje timeout → measure additional latency. 3. TLS concurrency — 5000 jednoczesnych TLS 1.3 connections do management API → verify all established → measure handshake distribution.

Session concurrency: 4. 500 jednoczesnych session creation requests → verify all sessions created → verify broker load distribution → measure creation time P99. 5. 200 jednoczesnych session terminations → verify all resources released → verify no orphaned workloads. 6. Mixed: 300 creates + 200 terminations + 500 active sessions → verify system stability under mixed workload.

Data concurrency: 7. 1000 jednoczesnych messages w Matrix → verify delivery order correct (per room) → verify no message loss → measure delivery latency. 8. 100 jednoczesnych policy evaluations → verify all evaluations correct → verify no stale policy reads. 9. 50 jednoczesnych config changes → verify eventual consistency → verify no config corruption.

Resource contention: 10. HSM signing contention — 500 jednoczesnych signing requests → verify HSM throughput → measure queuing delay. 11. Database connection pool contention — requests exceeding pool size → verify graceful queuing → verify no connection leak. 12. Disk I/O contention — heavy logging + backup + normal operations → verify log completeness → verify no data loss.

Wykrywanie problemów: - Race conditions: testy z helgrind/TSAN (Thread Sanitizer) w CI. - Deadlocks: timeout-based detection + thread dump analysis. - Priority inversion: monitoring priority queue fairness under load.

Progi: Każdy test ma defined acceptable degradation: P99 latency może wzrosnąć max 2× pod peak concurrency vs normal load. Error rate: 0% even under peak concurrency. Resource usage: within provisioned limits (no OOM, no disk full).

89.3 Session scale — skala sesji

Status: [N] Normatywny Odbiorca: QA, SRE, Architecture Wpływ na baseline: Krytyczny Powiązane rozdziały: 89.2, 89.4, 97.2

Testy skali sesji weryfikują zachowanie systemu przy rosnącej liczbie jednoczesnych sesji operatorów.

Scenariusze:

Progressive session load: 1. Ramp: 10 → 50 → 100 → 500 → 1000 → 2000 jednoczesnych sesji → per load level measure: session creation time, session quality (latency, jitter), broker CPU/memory, workload host CPU/memory, network throughput. 2. Session creation storm: 100 jednoczesnych session creation requests w

10s → verify all succeed → measure creation time distribution. 3. Steady-state at max capacity: maintain max sessions for 4h → verify no degradation (memory leak, connection pool exhaustion, disk growth).

Session quality under scale: 4. Per-session latency at 100 sessions vs 1000 sessions → verify P99 latency increase <20%. 5. Voice/video quality at scale: 50 jednoczesnych voice sessions → measure MOS score → verify MOS ≥4.0. 6. File transfer at scale: 20 jednoczesnych file transfers (10MB each) while 500 sessions active → verify no session quality degradation.

Per-tier targets:

Metric	STANDARD	PRO	STATE
Max concurrent sessions (per cluster)	500	1000	2000
Session creation P99	<5s	<3s	<2s
Session latency P99 at max	<100ms	<50ms	<30ms
Session stability (24h)	99.9%	99.95%	99.95%

Multi-tenant scale: 7. 50 tenants × 20 sessions each = 1000 sessions → verify tenant isolation maintained under load → verify no cross-tenant performance interference → verify per-tenant metrics accurate. 8. Large tenant + small tenant: tenant A with 500 sessions, tenant B with 10 sessions → verify tenant B's session quality not affected by tenant A's load (noisy neighbor prevention).

Failover at scale: 9. 1000 active sessions → kill 1 of 5 brokers → verify 200 sessions reallocated → verify total reallocation <60s → verify remaining session quality maintained.

89.4 Broker scale — skala brokera

Status: [N] Normatywny Odbiorca: QA, SRE, Architecture Wpływ na baseline: Wysoki Powiązane rozdziały: 89.3, 97.2, 97.3

Testy skali brokera weryfikują zdolność session brokerów do obsługi rosnącej liczby sesji i operatorów.

Scenariusze skali:

Single broker capacity: 1. Progressive load: 10 → 50 → 100 → 200 → 500 sesji na jednym brokerze → measure resource consumption (CPU, memory, network) per load level → identify saturation point. 2. Session management overhead: measure broker CPU/memory per session → determine theoretical max sessions per broker instance. 3. Heartbeat processing: broker receives heartbeats from all sessions co 10s → measure processing time at scale → verify no heartbeat loss at max capacity.

Horizontal scaling: 4. Start with 2 brokers, 200 sessions → add 3rd broker → verify sessions redistribute (gradually, no disruption) → verify load balancing improves. 5. Broker removal: 3 brokers → remove 1 → verify sessions migrate to remaining 2 → verify no session loss → measure migration time. 6. Rapid scaling: add 5 brokers simultaneously → verify discovery, registration, load balancing within 60s.

Failure at scale: 7. 1000 sessions across 5 brokers → kill 1 broker → verify 200 sessions reallocated to remaining 4 → measure total reallocation time → verify user interruption <10s per session. 8. Cascading broker failures: kill 2 of 5 brokers within 30s → verify system handles double failure → verify N+2 capacity sufficient.

State management: 9. Session state size per operator → measure broker memory growth → verify no memory leak over 72h sustained load test. 10. Session metadata query performance: admin queries all sessions for tenant → response time at 100 sessions, 1000 sessions, 5000 sessions.

Per-tier targets:

Metric	STANDARD	PRO	STATE
Sessions per broker	200	100	50
Reallocation time	<30s	<15s	<10s
Heartbeat processing P99	<100ms	<50ms	<20ms
Session create P99	<3s	<2s	<1s

STATE tier has fewer sessions per broker for higher quality of service and faster failover.

89.5 G1/G2 scale — skala gatewayów

Status: [N] Normatywny Odbiorca: QA, SRE, Network Engineering Wpływ na baseline: Wysoki Powiązane rozdziały: 89.1, 89.4, 88.2

Testy skali gatewayów G1 (network gateway) i G2 (application gateway) weryfikują ich zachowanie pod rosnącym obciążeniem.

G1 (Network Gateway) — skala:

Concurrent VPN tunnels: 100 → 500 → 1000 → 2000 jednoczesnych tuneli IKEv2 → measure: CPU, memory, tunnel setup time, DPD overhead.

Throughput per tunnel: 10 Mbps → 50 Mbps → 100 Mbps per tunel przy 500 tunelach → measure: aggregate throughput, per-tunnel latency, packet loss.

PQC overhead at scale: 1000 tuneli z hybrid PQC (ML-KEM + ECDH) → measure: additional handshake time (+15-20ms per handshake expected), CPU overhead for ML-KEM operations.

Rekey at scale: 500 tuneli rekey simultaneously (worst case: all tunnels created at same time, rekey interval identical) → verify no tunnel drops → measure rekey processing time.

DPD at scale: Dead Peer Detection for 2000 tunnels → verify DPD processing does not consume > 10% CPU.

G2 (Application Gateway) — skala:

Concurrent policy evaluations: 1000 → 5000 → 10,000 → 20,000 per second → measure: evaluation latency P99, G2 CPU, policy engine load.

Session routing: 500 → 2000 → 5000 concurrent sessions routed through G2 → measure: routing decision time, connection setup time.

Request throughput: mixed workload (API calls, file transfers, streaming) → 10,000 requests/s → measure: throughput, latency distribution, error rate.

Autoscaling response: load ramp from 0 to peak in 60s → verify G2 auto-scales within 120s → verify no request dropped during scaling.

Multi-tenant isolation at scale: 100 tenants × 50 sessions each → verify isolation maintained → verify no cross-tenant performance interference.

Combined G1+G2: 11. End-to-end: operator connects via VPN (G1) → authenticated and authorized (G2) → session established → data flowing → measure total setup time, steady-state latency. 12. Failure: G1 instance down → verify traffic rerouted → verify G2 sessions maintained → verify operator reconnects seamlessly.

89.6 Voice/video performance — latency, jitter, packet loss

Status: [N] Normatywny Odbiorca: QA, Platform Engineering Wpływ na baseline: Wysoki Powiązane rozdziały: 87.2, 89.5, 93.6

Testy voice/video mierzą jakość komunikacji real-time przez Matrix.

Targets:

Metryka	Target	Akceptowalne	Niedopuszczalne
Latency (one-way)	≤ 150ms	≤ 250ms	> 400ms
Jitter	≤ 30ms	≤ 50ms	> 100ms
Packet loss	≤ 0.5%	≤ 2%	> 5%
Audio MOS (Mean Opinion Score)	≥ 4.0	≥ 3.5	< 3.0

Test procedure: 1. Establish voice/video call between two synthetic endpoints. 2. Run for 15 minutes, measuring latency, jitter, packet loss. 3. Inject network impairments (10ms added latency, 1% packet loss) → verify graceful degradation. 4. Inject severe impairments (100ms latency, 5% loss) → verify call remains usable (audio). 5. Measure overhead of IPsec encryption on voice/video metrics.

89.7 Data services load — obciążenie usług danych

Status: [R] Rekomendowany Odbiorca: QA, SRE, Database Engineering Wpływ na baseline: Średni Powiązane rozdziały: 89.1, 89.3, 84.3

Testy obciążenia usług danych weryfikują wydajność i stabilność komponentów persystentnych pod obciążeniem produkcyjnym i ponadprodukcyjnym.

Komponenty testowane: 1. Matrix Synapse (baza komunikacji) — write throughput (messages/s), read throughput (sync requests/s), state resolution performance, media repository I/O. 2. IAM store — authentication requests/s, token validation throughput, policy evaluation latency. 3. Config store — read latency percentile, write throughput, watch/notification delivery latency. 4. Certificate/key store (HSM-backed) — signing operations/s, key generation throughput, attestation verification latency. 5. Telemetry store (Zone 4) — log ingestion rate (events/s), query latency for forensic queries, retention management overhead. 6. Backup store — backup write throughput, restore throughput, WORM verification overhead.

Scenariusze testowe: - Baseline load — symulacja typowego obciążenia produkcyjnego per tier (STANDARD: 100 concurrent users, PRO: 500, STATE: 1000). - Peak load — 3× baseline przez 30 minut. Weryfikacja czy system utrzymuje SLO. - Sustained load — baseline przez 72h. Weryfikacja braku memory leaks, connection pool exhaustion, disk growth anomalies. - Spike test — skok z idle do peak w <60s. Weryfikacja auto-scaling response time. - Data growth — symulacja 6 miesięcy akumulacji danych. Weryfikacja degradacji query performance z rosnącym dataset.

Metryki i proggi:

Komponent	Metryka	STANDARD	PRO	STATE
Matrix Synapse	Write latency P99	<200ms	<150ms	<100ms
IAM	Auth request P99	<100ms	<80ms	<50ms
Telemetry (Zone 4)	Ingestion	>5K events/s	>20K events/s	>50K events/s
HSM	Sign operations	>100/s	>500/s	>1000/s

Narzędzia: k6, Locust, custom load generators per komponent. Testy uruchamiane w dedicated performance environment (izolowanym od staging/prod). Wyniki archiwizowane — trend analysis kwartalnie.

89.8 Region failover performance

Status: [N] Normatywny Odbiorca: QA, SRE, Architecture Wpływ na baseline: Krytyczny Powiązane rozdziały: 79.5, 84.4, 97.5

Testy wydajności region failover mierzą czas i jakość przełączenia między regionami pod obciążeniem.

Scenariusze:

Full region failover under load: 1. 500 aktywnych sesji w primary region → simulate full region failure → measure: failover detection time, DNS propagation time, session recreation time w secondary, total downtime per operator. 2. Failover z PQC hybrid tunnels — dodatkowy czas na IKEv2 hybrid rekey w secondary region → measure PQC overhead during mass reconnection. 3. Data consistency — po failover, verify data in secondary region consistent with RPO target (per 84.3: STATE RPO 1h, PRO RPO 4h).

Failback performance: 4. After failover to secondary → primary region restored → failback initiated → measure: failback time, data resync time, session migration back. 5. Split-brain prevention — verify no split-brain scenario during failback → verify single source of truth maintained.

Partial degradation: 6. Primary region 50% degraded (half of nodes down) → verify system continues at reduced capacity → verify SLO maintained with degradation. 7. Network degradation between regions (100ms added latency) → measure impact on cross-region replication → verify data consistency.

Mass reconnection storm: 8. 1000 operators reconnecting simultaneously to secondary region → verify secondary can handle the spike → measure: session creation queue depth, wait time per operator, system stability. 9. Auto-scaling during failover — secondary region scales up to handle additional load → measure: scaling

time, time to full capacity.

Metryki i progi:

Metric	STANDARD	PRO	STATE
Total failover time	<5 min	<2 min	<1 min
Data loss (RPO)	<24h	<4h	<1h
Session recreation time	<60s	<30s	<15s
Post-failover SLO met	Within 10 min	Within 5 min	Within 2 min

Narzędzia: Chaos engineering tools (Gremlin, LitmusChaos) dla region failure injection. Custom load generators dla mass reconnection simulation. Full DR exercise (per 84.7) includes performance measurement.

89.9 Cost-performance tradeoffs

Status: [R] Rekomendowany Odbiorca: Architecture, Product Management, Finance Wpływ na baseline: Średni Powiązane rozdziały: 89.1, 89.4, 83.1

Analiza cost-performance tradeoffs pozwala na optymalne provisioning zasobów per tier bez over-provisioning.

Framework analizy:

Koszt per session: Rozbicie kosztu infrastruktury per aktywna sesja per tier: - Compute: microVM CPU/RAM allocation × stawka cloud provider. - Network: bandwidth per session × transfer cost. - Storage: ephemeral (session) + persistent (logs, config) per session. - Management overhead: broker, gateway, monitoring per session. - Security overhead: HSM operations, CDR processing, telemetry per session.

Marginal cost analysis: Dla każdego tier, zmierzyć marginal cost dodania jednego operatora: - STANDARD: target <60€/user/month infrastructure cost (3 VPS × 20€). - PRO: higher margin allows more resources per user. - STATE: premium pricing (2500€+) allows significant over-provisioning for security and performance.

Performance vs cost curves:

Dimension	Cost-effective point	Over-provisioned point	Risk of under-provisioning
Broker instances	N+1 redundancy	N+3	Session loss on failure
G1/G2 instances	Auto-scaled to load + 20%	Fixed over-provisioned	Slow session setup
HSM capacity	Peak + 30% headroom	2× peak	Signing delays
Network bandwidth	95th percentile + 20%	2× peak	Quality degradation
Storage (Zone 4)	6 months hot + cold archive	All hot	Unnecessary cost

Optimization strategies: 1. Right-sizing — analiza actual usage vs provisioned → identify over-provisioned resources → downsize. 2. Reserved vs on-demand — heavy baseline on reserved instances (cheaper), burst on on-demand. 3. Tiered storage — hot (SSD) for recent data, warm (HDD) for older, cold (archive) for compliance retention. 4. PQC cost — ML-KEM adds ~15ms latency but negligible CPU cost; ML-DSA signing ~2× slower than ECDSA → factor into HSM capacity planning. 5. Auto-scaling efficiency — measure scaling response time vs cost → tune scaling policies per tier.

Quarterly review: Cost-performance dashboard reviewed quarterly. Action: identify resources >30% over-provisioned → resize. Identify resources >80% utilized → plan scaling. Per-tier cost per operator tracked monthly.

Rozdział 90. Testy bezpieczeństwa i prywatności

90.1 Terminal security validation

Status: [N] Normatywny Odbiorca: Security, QA Wpływ na baseline: Krytyczny Powiązane rozdziały: 86.2, 87.2, 90.2

Testy bezpieczeństwa terminala weryfikują, że thin client device nie pozwala na ekstrakcję danych ani obejście zabezpieczeń.

Test cases: 1. Boot integrity: terminal bootuje wyłącznie z podpisanego firmware (secure boot verification). 2. No local storage access: operator nie może zapisać danych na lokalnym dysku terminala. 3. USB restriction: unauthorized USB devices (storage, network adapters) blokowane. 4. Screen capture: screenshot/screen recording zablokowane na terminalu. 5. Clipboard isolation: clipboard nie może być eksportowany poza sesję (copy z sesji → paste poza sesją blocked). 6. Network restriction: terminal komunikuje się wyłącznie z G1 gateway (no direct internet, no local network access). 7. Certificate pinning: terminal akceptuje wyłącznie certyfikaty zaufanego CA SYLION. 8. Firmware tamper detection: modified firmware → terminal refuses to boot lub alerts.

Narzędzia testowe: Fizyczny test z access do terminala (attempt extraction), network analysis (wireshark on terminal network), USB device injection test.

90.2 Router leak tests — kill switch, DNS leak, WebRTC leak

Status: [N] Normatywny Odbiorca: Security, QA, Network Engineering Wpływ na baseline: Krytyczny Powiązane rozdziały: 86.3, 90.1, 90.3

Testy wycieków routera weryfikują, że ruch operatora nigdy nie wychodzi poza tunel VPN.

Test cases: 1. Kill switch: IPsec tunnel drops → router blokuje CAŁY ruch (nie dopuszcza ruchu poza tunel). Operator traci łączność (expected) zamiast routingu po niezabezpieczonej ścieżce. 2. DNS leak: DNS queries idą wyłącznie przez tunel (sprawdzenie: dnsleak.test z sesji → zero external DNS resolvers). 3. WebRTC leak: jeśli przeglądarka używana w sesji, WebRTC nie ujawnia real IP operatora (STUN binding request → only tunnel IP visible). 4. IPv6 leak: IPv6 traffic blokowany na routerze (jeśli nie tunelowany) — zapobiega wyciekowi przez IPv6 bypass. 5. Split tunnel prevention: router nie pozwala na split tunneling — cały ruch przez tunel, bez wyjątków. 6. MTU handling: duże pakiety prawidłowo fragmentowane wewnątrz tunelu, bez leaku niezasyfrowanych fragmentów.

Automatyzacja: Testy uruchamiane automatycznie po każdej zmianie firmware routera. Narzędzia: custom test scripts na testowym routerze z packet capture na wszystkich interfejsach.

90.3 G1/G2 attack surface validation

Status: [N] Normatywny Odbiorca: Security, Penetration Testing, Architecture Wpływ na baseline: Krytyczny Powiązane rozdziały: 88.2, 89.5, 90.1

G1 i G2 są primary attack surface SYLION — jedyne komponenty bezpośrednio wystawione na internet. Walidacja ich attack surface jest krytyczna.

G1 (Network Gateway) — attack surface: 1. Port scanning — verify only required ports open (IKEv2: UDP 500, 4500; management: none externally). All other ports closed and filtered (no ICMP, no TCP). 2. IKEv2 fuzzing — malformed IKE_SA_INIT packets, oversized payloads, invalid proposals → verify G1 does not crash, does not leak information, responds correctly (or drops silently). 3. DDoS resilience — flood of IKE_SA_INIT requests (10,000/s) → verify G1 rate limits, does not exhaust resources, continues serving legitimate clients. 4. Certificate validation — expired certificates, revoked certificates, self-signed certificates, wrong CA → verify rejection. 5. Downgrade attack — attacker forces negotiation to weaker algorithms → verify G1 rejects below minimum threshold (no 3DES, no SHA-1, no DH group <14). 6. PQC hybrid bypass — attempt to negotiate non-hybrid when hybrid required by policy → verify enforcement.

G2 (Application Gateway) — attack surface: 7. Authentication bypass — attempts to access resources without valid token → verify 401. 8. Authorization bypass — valid token but unauthorized resource → verify 403. 9. Session hijacking — replay of old session tokens, session fixation → verify prevention. 10. Input validation — SQL injection, XSS, command injection via all input fields → verify sanitization. 11. Rate limiting — brute force authentication, API abuse → verify rate limiting effective. 12. Information leakage — error messages, headers, timing → verify no sensitive information in responses.

Combined attack scenarios: 13. Lateral movement — compromised G1 → attempt to reach G2 internal interfaces → verify network segmentation prevents. 14. Man-in-the-middle — attempt MITM on G1↔G2 internal communication → verify mTLS enforced. 15. State exhaustion — create maximum half-open sessions → verify G1/G2 handle gracefully, existing sessions unaffected.

Frequency: Automated scans weekly. Manual penetration testing: quarterly for G1/G2 specifically. Red team exercise: annually targeting G1/G2 as entry points.

90.4 Workload isolation tests — breakout attempts

Status: [N] Normatywny Odbiorca: Security, Architecture, Penetration Testing Wpływ na baseline: Krytyczny Powiązane rozdziały: 88.3, 97.4, 90.3

Workload isolation jest fundamentem bezpieczeństwa SYLION — każdy operator pracuje w izolowanym microVM. Testy weryfikują że izolacja jest skuteczna.

Breakout attempts: 1. VM escape — próba przejścia z microVM (Firecracker) do hosta. Test: exploitation znanych CVE (historical, patched — regression), custom exploit attempts, syscall fuzzing via seccomp bypass. 2. Container escape — jeśli workload contains containers within microVM → test container → VM boundary. 3. Filesystem escape — attempt to read/write host filesystem from within microVM. Verify: no host filesystem mounted, virtio-blk isolated. 4. Network escape — attempt to reach other tenants' microVMs, host network, management network from within workload. Verify: network namespace isolation, no routing to other VMs, no access to metadata services. 5. Memory isolation — attempt to read other VM's memory. For STATE tier with TEE: verify AMD SEV-SNP / Intel TDX prevents host from reading VM memory. 6. Side-channel — timing attacks, cache-based side channels (Spectre/Meltdown variants) → verify mitigations active (microcode, kernel patches, TEE isolation).

Cross-tenant isolation: 7. Data isolation — tenant A's workload attempts to access tenant B's storage, config, keys → verify denied at all layers. 8. Network isolation — tenant A's workload attempts to communicate with tenant B's workload → verify no connectivity. 9. Resource isolation — tenant A's workload consumes maximum resources → verify no impact on tenant B's performance (noisy neighbor prevention).

TEE-specific tests (STATE tier): 10. Attestation spoofing — attempt to present fake attestation report → verify detection. 11. Memory encryption verification — verify guest memory encrypted at rest (SEV-SNP memory encryption active). 12. Integrity verification — verify guest memory integrity (SEV-SNP RMP table correct).

Frequency: Automated isolation tests: daily. Manual breakout testing: quarterly. Full red team with breakout focus: annually. Any new Firecracker version or kernel update triggers full isolation regression suite.

90.5 File pipeline abuse tests — CDR bypass attempts

Status: [N] Normatywny Odbiorca: Security, QA, CDR Engineering Wpływ na baseline: Krytyczny Powiązane rozdziały: 90.4, 88.7, 87.1

CDR (Content Disarm and Reconstruction) pipeline jest krytycznym komponentem bezpieczeństwa — testy weryfikują że nie może być obejściowa.

Bypass attempts:

File format evasion: 1. Polyglot files (file valid as multiple formats, e.g., JPEG + ZIP) → verify CDR processes correctly, no executable content survives. 2. Nested archives (ZIP within ZIP within ZIP, >10 levels) → verify CDR handles depth limit → verify no zip bomb decompression. 3. Encrypted archives (password-protected ZIP/RAR) → verify CDR blocks or quarantines (cannot inspect encrypted content). 4. Filename manipulation — double extensions (.pdf.exe), unicode override characters (RLO), very long filenames → verify correct handling. 5. MIME type mismatch — file with .pdf extension but executable content → verify CDR detects by content inspection, not extension.

Embedded content: 6. Macros in Office documents → verify macros stripped. 7. Embedded OLE objects → verify removed or sanitized. 8. JavaScript in PDF → verify removed. 9. Active content in HTML → verify sanitized (scripts, iframes, forms removed). 10. Embedded executables in any format → verify removed.

Evasion techniques: 11. Very large files (>1GB) → verify CDR handles or rejects with clear error (no timeout exploitation). 12. Corrupted files (truncated headers, invalid structures) → verify CDR rejects (fail-closed, not fail-open). 13. Steganography — data hidden in image pixels → CDR may not detect (acceptable limitation, documented). 14. Slow-drip upload — very slow upload attempting to exhaust CDR resources → verify timeout and cleanup.

Pipeline integrity: 15. File submitted → CDR processing → reconstructed file → verify reconstructed file opens correctly in target application. 16. Document fidelity — original vs reconstructed: verify visual similarity (automated comparison), verify no content loss (text extraction comparison). 17. Throughput under abuse — 100 malicious files simultaneously → verify CDR processes all, no crash, no bypass.

Reporting: Every blocked file logged with: reason, original hash, file type detected, timestamp. Monthly report of CDR statistics to CISO.

90.6 Session abuse tests

Status: [N] Normatywny Odbiorca: Security, QA, Architecture Wpływ na baseline: Wysoki Powiązane rozdziały: 88.4, 90.4, 97.2

Session abuse tests weryfikują odporność mechanizmu sesji na manipulację i nadużycia.

Scenariusze:

Session hijacking: 1. Replay ataku — przechwycony session token użyty ponownie → verify token binding (IP, device fingerprint) prevents reuse. 2. Session fixation — attacker sets session ID before authentication → verify session ID regenerated after authentication. 3. Token theft simulation — valid token extracted from memory → verify short token lifetime (15 min) limits exposure → verify token refresh requires re-authentication. 4. Cross-session interference — manipulate session A to affect session B → verify complete isolation.

Session resource abuse: 5. Session hoarding — single user creates maximum concurrent sessions → verify limit enforced → verify old sessions terminated. 6. Long-lived idle sessions — session kept alive indefinitely without activity → verify idle timeout enforced (configurable, default 30 min). 7. Resource exhaustion via session — operator in session attempts to consume excessive CPU/RAM → verify resource limits enforced per microVM → verify no impact on other sessions. 8. Bandwidth abuse — operator attempts to transfer excessive data → verify bandwidth limits per session → verify throttling, not disconnection.

Session lifecycle abuse: 9. Rapid connect/disconnect cycling — 100 connect/disconnect cycles in 1 minute → verify system handles gracefully → verify no resource leak (orphaned VMs, connections). 10. Concurrent sessions from different locations — same operator simultaneously from 2 IPs → verify policy enforcement (allow/deny per configuration). 11. Session during maintenance — operator session active when maintenance begins → verify graceful handling (notification, migration, not abrupt termination). 12. Session across region failover — active session during region failover → verify session recreated in secondary → verify data consistency.

Privilege escalation: 13. Operator attempts to access admin functions via session → verify RBAC enforcement. 14. Operator modifies session metadata (tenant ID, role) → verify server-side validation, client-side values ignored.

Frequency: Automated abuse tests in CI/CD. Manual exploitation testing quarterly.

90.7 Privacy leakage tests

Status: [N] Normatywny Odbiorca: Security, Privacy/DPO, QA Wpływ na baseline: Krytyczny Powiązane rozdziały: 94.5, 90.8, 90.9

Privacy leakage tests weryfikują, że SYLION nie ujawnia danych osobowych ani prywatnych treści operatorów w sposób niezamierzony.

Scenariusze:

Content leakage: 1. E2E encryption verification — messages in transit: capture network traffic → verify encryption (no plaintext content). Messages at rest: inspect database → verify encrypted (Megolm/Olm session keys, not plaintext). 2. File content leakage — uploaded files: verify encrypted in transit and at rest → verify CDR processing doesn't store unencrypted copies persistently → verify temp files cleaned after processing. 3. Clipboard leakage — operator copies sensitive data → verify clipboard content not logged, not transmitted outside session, not cached on server. 4. Screen content leakage — verify no screenshots or screen captures stored server-side (thin client architecture: screen content transmitted as pixels, not stored).

Metadata leakage: 5. User identity in logs — verify logs contain user IDs (pseudonymized), not names or emails. 6. IP addresses in logs — verify IP addresses hashed or truncated per privacy policy. 7. Communication patterns — verify metadata (who communicates with whom, when, how often) not accessible to platform operators without authorized investigation.

Cross-tenant leakage: 8. Tenant A admin cannot see tenant B's users, sessions, or any data. 9. Aggregated metrics (platform-wide) do not reveal individual tenant data. 10. Error messages do not contain other tenants' identifiers or data.

Regulatory compliance: 11. GDPR data subject access request (DSAR) — verify system can export all data for a specific user → verify export complete and accurate. 12. GDPR right to erasure — verify user data can be deleted → verify deletion propagates to all stores (including backups within retention policy). 13. Data minimization — verify system collects only necessary data per defined purpose → audit data fields against purpose documentation.

Testing methodology: Automated data flow analysis (taint tracking), manual inspection of logs and databases, privacy impact assessment per new feature.

90.8 Metadata leakage tests

Status: [N] Normatywny Odbiorca: Security, Privacy/DPO, Architecture Wpływ na baseline: Wysoki Powiązane rozdziały: 90.7, 94.5, 93.1

Metadata leakage jest subtelniejszy niż content leakage — nawet bez dostępu do treści, metadata może ujawnić wrażliwe informacje.

Scenariusze:

Communication metadata: 1. Timing analysis — obserwacja timestampów wiadomości pozwala wnioskować o wzorcach komunikacji. Test: verify timestamps nie mają nadmiernej precyzji w external-facing interfaces (round to minute, not nanosecond). 2. Volume analysis — ilość danych przesyłanych wskazuje na typ aktywności (duży transfer = pliki, ciągły stream = video). Test: verify traffic padding opcja dostępna dla STATE tier (uniform packet sizes). 3. Social graph — who communicates with whom, even without content, reveals organizational structure. Test: verify Matrix federation metadata minimized, room membership not queryable externally. 4. Presence information — online/offline status, last seen timestamps → verify configurable per tenant (can be disabled for STATE tier).

Network metadata: 5. DNS leakage — DNS queries reveal visited domains. Test: verify all DNS queries go through encrypted resolver (DoH/DoT), not system resolver. 6. TLS SNI leakage — Server Name Indication in TLS handshake reveals destination. Test: verify ECH (Encrypted Client Hello) supported where available. 7. IP metadata — source/destination IPs reveal communication endpoints. Test: verify VPN tunnel encrypts at network layer, no direct connections bypassing tunnel. 8. Traffic pattern — timing and volume patterns of VPN traffic. Test: verify optional traffic padding for STATE tier.

Operational metadata: 9. Session metadata — session duration, start/end times, device type → verify not exposed beyond necessary scope (admin of that tenant only). 10. Error metadata — error messages may contain internal system details → verify sanitized before reaching operator. 11. Certificate metadata — certificate subjects, SANs may reveal internal infrastructure → verify minimized.

Mitigation validation: 12. Verify metadata minimization per telemetry layer (94.5). 13. Verify audit logs contain only necessary metadata for investigation. 14. Verify external APIs (tenant-facing) return minimal metadata.

90.9 Telemetry minimization tests

Status: [N] Normatywny Odbiorca: Security, Privacy/DPO, SRE Wpływ na baseline: Wysoki Powiązane rozdziały: 94.5, 93.1, 90.7

Telemetry minimization zapewnia, że system monitoringu zbiera wyłącznie dane niezbędne do operacji, bez nadmiernej inwigilacji operatorów.

Testy:

Content exclusion: 1. Verify: no message content in any telemetry stream (logs, metrics, traces, events). Test: send known message → search all telemetry stores for message content → must not be found. 2. Verify: no file content in telemetry. Test: upload known file → search telemetry for file content/hashes → must not be found (CDR logs may contain hash for security, but not content). 3. Verify: no clipboard content in telemetry. 4. Verify: no screen content in telemetry (no screenshots, no OCR of operator screens).

PII minimization: 5. Verify: user identifiers in telemetry are pseudonymized (internal IDs, not names/emails). 6. Verify: IP addresses in telemetry follow privacy policy (hashed, truncated, or retained only in Zone 4 with restricted access). 7. Verify: device identifiers not linkable to physical person without IAM access. 8. Verify: no biometric data in telemetry (no voice recordings, no keystroke dynamics).

Proportionality: 9. Verify: telemetry granularity appropriate to purpose. Example: session quality metric sufficient as aggregate (avg latency per 5 min), not per-keystroke timing. 10. Verify: sampling rules (94.1) applied — not all events at maximum granularity. 11. Verify: tenant-configurable telemetry (tenant can opt out of non-security telemetry where allowed by operations needs).

Retention: 12. Verify: telemetry retention follows defined policy (hot: 7 days, warm: 30 days, cold: per compliance). 13. Verify: expired telemetry automatically purged. 14. Verify: forensic retention mode (94.7) requires explicit activation and is time-limited.

Audit: 15. Quarterly privacy review of all telemetry fields — new field added requires privacy assessment. 16. Annual telemetry minimization audit by DPO or external privacy assessor.

Rozdział 91. Kryteria akceptacji i readiness do produkcji

91.1 Production readiness review checklist

Status: [N] Normatywny Odbiorca: Engineering Leadership, SRE, Security Wpływ na baseline: Krytyczny Powiązane rozdziały: 91.2, 91.3, 91.7

Production Readiness Review (PRR) to formalny gate przed wdrożeniem nowej major version lub nowego komponentu do produkcji.

Checklist: - [] Wszystkie testy E2E pass (87.). - [] Security regression pass (81.4, 90.). - [] Performance benchmarks w normie (89.). - [] Contract tests pass (81.1, 88.). - [] Infrastructure provisioned i validated (IaC tested, drift-free). - [] Monitoring i alerting configured (93., 95.). - [] Runbooks written and reviewed (95.3). - [] On-call rotation scheduled i briefed. - [] Rollback plan documented i tested. - [] Customer communication prepared (84.9). - [] Compliance review complete (91.4). - [] Documentation updated (91.5). - [] Training complete (91.6).

Proces: PRR meeting: Engineering Lead + SRE Lead + Security Lead + Product Owner. Każdy punkt checklista reviewed. Single "not ready" → deploy blocked until resolved.

91.2 Security readiness review

Status: [N] Normatywny Odbiorca: CISO, Security, Architecture Wpływ na baseline: Krytyczny Powiązane rozdziały: 91.1, 90.1, 78.1

Security readiness review jest dedykowaną oceną gotowości bezpieczeństwa przed dopuszczeniem do produkcji. Osobny track od ogólnej production readiness.

Checklist:

Cryptography: - [] All transport encrypted (TLS 1.3, IKEv2 IPsec) — no plaintext channels. - [] PQC hybrid profile active per tier policy (73.7). - [] HSM operational, FIPS 140-3 validated, keys generated and stored securely. - [] Certificate chain complete and valid, automated renewal configured. - [] AES-256 for data at rest, SHA-384+ for hashing.

Access control: - [] Zero Trust architecture implemented — no implicit trust. - [] MFA enforced for all admin accounts, configurable for operators. - [] RBAC implemented and tested (per 92.4 policy testing). - [] Tenant isolation verified (per 90.4). - [] Least privilege enforced — no over-permissioned accounts.

Vulnerability management: - [] All components scanned (SAST, SCA) — zero critical/high findings. - [] Penetration test completed within last 90 days — all findings remediated or risk-accepted by CISO. - [] Dependency audit — no known critical CVEs in production dependencies. - [] OS/firmware hardened per CIS benchmarks.

Monitoring and detection: - [] SOC operational, alerts configured and tested. - [] Security telemetry flowing to SIEM (per 88.6). - [] Incident response plan documented and tested (per 95.4). - [] Log integrity (Zone 4) operational — tamper detection active.

Compliance: - [] ISO 27001 controls mapped and evidenced. - [] GDPR compliance verified (DPO review). - [] Sector-specific compliance (if applicable) verified. - [] PQC compliance per CNSA 2.0 timeline (per 74.10).

Sign-off: CISO must sign off security readiness review. Any open critical finding = no-go. Open high findings require documented risk acceptance with remediation deadline.

91.3 Operational readiness review

Status: [N] Normatywny Odbiorca: SRE, Operations, Engineering Leads Wpływ na baseline: Wysoki Powiązane rozdziały: 91.1, 83.1, 84.1

Operational readiness review weryfikuje, że zespoły i procesy operacyjne są gotowe do utrzymania systemu w produkcji.

Checklist:

Monitoring and alerting: - [] SLI/SLO zdefiniowane per komponent (per 83.1). - [] Alerting skonfigurowany i przetestowany — all critical paths covered. - [] Dashboards operational — executive, operational, security, tenant-visible (per 83.5). - [] Error budgets zdefiniowane i tracking aktywny (per 83.2).

Incident response: - [] On-call rotation established — minimum 2 people per rotation. - [] Escalation matrix documented i contacts verified (per 85.7). - [] Runbooks per komponent complete i tested (per 95.3). - [] Incident management tooling configured (PagerDuty/Opsgenie, incident channel). - [] Post-mortem process documented (per 96.1).

Backup and DR: - [] Backup configured and tested — automated restore verified (per 84.5). - [] RPO/RTO per tier defined i achievable (per 84.3, tested per 87.6). - [] DR plan documented and tested within last 6 months (per 84.7). - [] Immutable backups operational (per 84.6).

Deployment: - [] CI/CD pipeline operational, all gates active (per 80.1). - [] Rollback procedure tested (per 80.9). - [] Deployment runbook documented. - [] Feature flags operational for new features (per 82.4).

Capacity: - [] Capacity baseline established per component. - [] Auto-scaling configured and tested. - [] Cost monitoring active — budget alerts configured. - [] Capacity runway: ≥ 3 months at current growth rate.

Team readiness: - [] All on-call engineers trained (per 91.6). - [] Bus factor ≥ 2 for every critical system. - [] Knowledge base / wiki up to date.

Sign-off: SRE Lead + Engineering Lead must sign off. Open critical items = no-go.

91.4 Compliance readiness review

Status: [N] Normatywny Odbiorca: Compliance, Legal, CISO, DPO Wpływ na baseline: Wysoki Powiązane rozdziały: 91.1, 91.2, 74.10

Compliance readiness review weryfikuje spełnienie wymagań regulacyjnych i certyfikacyjnych przed uruchomieniem produkcji.

Checklist per framework:

ISO 27001: - [] Statement of Applicability (SoA) aktualne — all applicable controls listed. - [] Risk assessment completed — risk register up to date. - [] Controls implemented i evidenced — evidence per control (logs, configs, test results). - [] Internal audit completed within last 12 months (or pre-certification audit). - [] Management review conducted.

GDPR: - [] Data Processing Agreement (DPA) template ready for tenants. - [] Privacy Impact Assessment (PIA/DPIA) completed for SYLION processing. - [] Data Subject Access Request (DSAR) process operational and tested (90.7). - [] Right to erasure process operational and tested. - [] Data breach notification process documented (72h deadline). - [] DPO appointed and operational. - [] Records of processing activities (ROPA) maintained.

CNSA 2.0 (for STATE tier): - [] PQC algorithms implemented per timeline (74.10). - [] FIPS 140-3 validated HSM operational. - [] Cryptographic Bill of Materials (CBOM) current (per 74.2). - [] Crypto-agility demonstrated (74.1).

Sector-specific (if applicable): - [] Healthcare (HIPAA equivalent) — encryption, access control, audit logging. - [] Financial (PCI DSS, sector regs) — segmentation, encryption, monitoring. - [] Government/Defense — clearance requirements, data residency, classification handling.

Evidence management: - Compliance evidence stored in dedicated, access-controlled repository. - Evidence linked to specific controls — auditor can trace control → evidence. - Automated evidence collection where possible (e.g., configuration snapshots, scan results). - Evidence freshness: most evidence <30 days old at time of review.

Sign-off: Compliance Officer + CISO + DPO (for GDPR) must sign off. Open critical compliance gap = absolute no-go.

91.5 Documentation readiness review

Status: [N] Normatywny Odbiorca: Technical Writing, Engineering Leads, Product Management Wpływ na baseline: Wysoki Powiązane rozdziały: 91.1, 91.6, 85.1

Dokumentacja musi być kompletna i aktualna przed dopuszczeniem systemu do produkcji. Brak dokumentacji jest blokerem go-live.

Wymagane dokumenty:

Dokumentacja operacyjna (internal): 1. Architecture Decision Records (ADR) — aktualne, pokrywające wszystkie kluczowe decyzje. 2. Runbooki per komponent — przetestowane, z linkami do alertów (per 95.3). 3. Playbooki per incident type — przetestowane (per 95.4, 95.7). 4. Deployment procedures — krok po kroku, tested by someone who didn't write them. 5. DR procedures — przetestowane, aktualne (per 84.7). 6. On-call handbook — eskalacje, kontakty, narzędzia, dostępy. 7. Capacity planning documentation — current baselines, scaling procedures.

Dokumentacja techniczna (internal/partner): 8. API documentation — OpenAPI specs, aktualne, z przykładami. 9. Integration guides — per supported integration (SIEM, IdP, etc.). 10. Security architecture documentation — threat model, security controls mapping. 11. Network architecture — diagrams, IP plans, firewall rules documentation.

Dokumentacja klienta (external): 12. User guide — per operator role, per admin role. 13. Quick start guide — onboarding new tenant. 14. FAQ / troubleshooting — top 20 issues with resolution steps. 15. SLA documentation — per tier, z metodyką pomiaru. 16. Security whitepaper — architektura bezpieczeństwa, certyfikacje, compliance.

Kryteria akceptacji: - Wszystkie dokumenty listed above istnieją i mają datę aktualizacji <30 dni od go-live. - Runbooki i playbooki przetestowane (evidence: test report per 95.7). - API docs wygenerowane automatycznie z kodu (OpenAPI) — brak manual drift. - Security documentation reviewed by CISO. - Customer-facing docs reviewed by Product Management i Technical Writing. - Tłumaczenia (jeśli wymagane per market) kompletne i reviewed.

Review process: Documentation review jest częścią Production Readiness Review (91.1). Brakująca dokumentacja = blocker. Nieaktualna dokumentacja (>60 dni) = warning z 14-dniowym deadline na aktualizację.

91.6 Training readiness review

Status: [N] Normatywny Odbiorca: HR/Training, Engineering Leads, Support Wpływ na baseline: Wysoki Powiązane rozdziały: 91.1, 91.5, 85.1

Zespoły operacyjne, support i security muszą być przeszkolone przed dopuszczeniem systemu do produkcji.

Wymagane szkolenia:

Zespół SRE/Operations: 1. Architecture overview — zrozumienie komponentów, flow danych, zależności. 2. Deployment procedures — hands-on w środowisku staging. 3. Monitoring i alerting — nawigacja po dashboardach, interpretacja alertów. 4. Incident response — przejście przez playbooki, role, eskalacje. 5. DR procedures — hands-on DR exercise w staging. 6. On-call procedures — shadowing doświadczonego on-call przez minimum 1 tydzień.

Zespół Support (L1/L2): 7. Product training — funkcjonalność z perspektywy użytkownika/admina. 8. Troubleshooting — top 20 issues, diagnostic tools, log reading. 9. Escalation procedures — kiedy i jak eskalować do L3. 10. Customer communication — templates, tone, SLA awareness.

Zespół Security/SOC: 11. Security architecture — threat model, controls, monitoring points. 12. Security incident response — SOC playbooks, forensic procedures. 13. Compliance requirements — regulacje, audyty, evidence collection. 14. PQC awareness — nowe algorytmy, hybrid mode, monitoring.

Kryteria akceptacji: - Każdy on-call engineer ukończył szkolenia 1–6 i zdał test praktyczny (samodzielne rozwiązanie symulowanego incydentu w staging). - Każdy support L1/L2 ukończył szkolenia 7–10 i zdał test (samodzielna obsługa 5 scenariuszy). - Każdy SOC analyst ukończył szkolenia 11–14. - Training completion tracked w LMS (Learning Management System). - Minimum 2 osoby per rola przeszkolone (bus factor ≥2). - Training materials aktualne (<30 dni od go-live).

Continuous training: Post-go-live: kwartalne refresher training, obowiązkowe po major architecture changes. Nowi członkowie zespołu: onboarding program z dedicated buddy przez 2 tygodnie. Training effectiveness mierzona: czas do samodzielnego dyżuru on-call (target: <4 tygodnie od onboarding).

91.7 Customer go-live checklist

Status: [N] Normatywny Odbiorca: Customer Success, Operations, Sales Wpływ na baseline: Wysoki Powiązane rozdziały: 91.1, 85.1, 86.6

Customer go-live checklist weryfikuje gotowość per tenant przed aktywacją produkcyjnej — osobna od platform readiness.

Pre-go-live (per tenant):

Contractual: - [] Contract signed — tier, SLA, scope, data residency, support level. - [] DPA signed (GDPR requirement). - [] NDA signed (if required). - [] Billing configured — payment method verified, initial invoice generated.

Technical provisioning: - [] Tenant environment provisioned (per 86.6). - [] Network connectivity verified — VPN tunnel established, latency acceptable. - [] Identity integration configured — IdP connected (SAML/OIDC), test user authenticated successfully. - [] Admin accounts created and MFA enabled. - [] Initial operators provisioned (minimum 2 for testing). - [] E2E test: operator connects → session created → communication works → file transfer works → session ends.

Security: - [] Security policy per tenant configured (per 82.1, 88.2). - [] Encryption profile configured per tier (classical/hybrid PQC/full PQC). - [] Tenant isolation verified (per 90.4 — cross-tenant test). - [] CDR policy configured per tenant requirements. - [] SIEM export configured (if tenant has external SIEM).

Operations: - [] Monitoring active for tenant environment — dashboards operational. - [] Alerting configured — tenant-specific alerts where applicable. - [] Backup verified — first backup successful, restore tested. - [] Support channel established — tenant knows how to reach support. - [] Status page access provided.

Training: - [] Admin training delivered. - [] Operator quick-start guide provided. - [] Support contact information shared.

Sign-off: Customer Success Manager + Tenant Admin + Technical Lead sign off on go-live. Post-go-live: daily health check for first 7 days, weekly for first month.

Rozdział 92. Automatyzacja testów i pokrycie

92.1 Coverage model — model pokrycia testowego

Status: [N] Normatywny Odbiorca: QA, Engineering Leads, CISO Wpływ na baseline: Wysoki Powiązane rozdziały: 92.2, 92.6, 91.1

Model pokrycia testowego definiuje, jakie aspekty systemu muszą być przetestowane, z jaką głębokością i przy jakim budżecie.

Wymiary pokrycia:

Functional coverage — % zdefiniowanych wymagań funkcjonalnych objętych testami. Target: 100% dla krytycznych, ≥95% dla high, ≥80% dla medium.

Code coverage — % linii/branch kodu objętych unit testami. Target: ≥80% line coverage, ≥70% branch coverage. Nie jako cel sam w sobie, ale jako minimum quality bar.

Security control coverage — % kontroli bezpieczeństwa z automatycznym testem (per 92.6). Target: 100% dla krytycznych kontroli.

Policy coverage — % polityk z automatycznym testem (per 92.4). Target: 100%.

Contract coverage — % interfejsów z kontraktem (per 92.5). Target: 100% dla krytycznych.

Infrastructure coverage — % IaC modules z testami (per 92.3). Target: 100%.

Failure mode coverage — % zidentyfikowanych failure modes z testem (chaos engineering). Target: ≥80%.

Compliance coverage — % kontroli compliance z automated evidence. Target: ≥70%.

Model piramidy:

/ E2E \ 5-10% test budget / Integr. \ 20-30% test budget / Unit \ 60-70% test budget

E2E testy są najdroższe (slow, flaky, hard to maintain) — pokrywają critical paths. Integration testy pokrywają interfejsy. Unit testy pokrywają logic.

Coverage tracking: - Automated coverage reports generated per pipeline run. - Coverage dashboard per komponent, per team. - Coverage trend — declining coverage triggers investigation. - Coverage minimum enforced in CI — PR that decreases coverage below threshold is blocked.

Exceptions: Niektóre obszary celowo mają niższe pokrycie: legacy integrations (maintenance mode), experimental features ([E] status), third-party components (tested at integration boundary, not internally).

92.2 Unit vs integration vs E2E ratio targets

Status: [R] Rekomendowany Odbiorca: QA, Engineering Leads, Architecture Wpływ na baseline: Średni Powiązane rozdziały: 92.1, 92.7, 80.3

Proporcje między typami testów wpływają na szybkość feedbacku, koszt utrzymania i coverage.

Target ratio (test budget distribution):

Test type	% test count	% execution time	Feedback time
Unit tests	60-70%	5-10%	<5 min (per PR)
Integration tests	20-30%	20-30%	<15 min (per PR)

E2E tests	5-10%	50-70%	<60 min (per deploy)
-----------	-------	--------	----------------------

Per-component targets:

Component	Unit	Integration	E2E	Uzasadnienie
Business logic (IAM, policy engine)	80%	15%	5%	Heavy logic, lightweight I/O
Infrastructure (IaC, config)	20%	70%	10%	Value in integration, not unit
Security (crypto, auth)	60%	30%	10%	Both algorithm correctness and integration
UI (admin portal)	30%	20%	50%	UI testing best at E2E level
Data services (Matrix, DB)	50%	40%	10%	Integration with storage critical

Anti-patterns (unikac): 1. Ice cream cone — more E2E than unit → slow feedback, flaky tests, expensive maintenance. Symptom: CI pipeline takes >2h. 2. Unit-only pyramid — 99% unit, no integration → false confidence, integration bugs in production. Symptom: "all tests pass but production broken." 3. No pyramid at all — ad-hoc testing without strategy → gaps, duplicates, inconsistent coverage.

Monitoring ratio: - CI dashboard shows test count and execution time per type per component. - Quarterly review: are ratios within target? If not — action plan. - New component requires test strategy document before first PR — defining target ratio.

Flaky test policy: Flaky tests (inconsistent pass/fail) quarantined within 48h. Quarantine = test disabled with ticket and 14-day fix deadline. Unresolved flaky tests deleted after 30 days.

92.3 IaC testing

Status: [N] Normatywny Odbiorca: DevOps, SRE, Security Wpływ na baseline: Wysoki Powiązane rozdziały: 79.4, 82.8, 92.1

IaC (Infrastructure as Code) testing zapewnia, że infrastruktura provisionowana przez Terraform/Pulumi jest poprawna, bezpieczna i spójna.

Poziomy testów IaC:

Static analysis (pre-plan): 1. Linting — terraform validate, tfLint → syntax errors, deprecated features, naming conventions. 2. Security scanning — tfsec, checkov, terrascan → detect insecure configurations (public S3, missing encryption, overly permissive security groups). 3. Policy compliance — OPA/Sentinel policies → verify IaC meets organizational policies (e.g., all resources tagged, all storage encrypted, no public IPs without approval). 4. Cost estimation — Infracost → estimate cost of planned changes → alert if >20% cost increase.

Plan validation (post-plan, pre-apply): 5. Plan diff review — automated analysis of terraform plan output: what's created, modified, destroyed → flag unexpected changes (e.g., resource recreation that should be update). 6. Drift detection — compare plan with actual state → detect manual changes not reflected in IaC. 7. Dependency check — verify no circular dependencies, no orphaned resources. 8. Blast radius assessment — how many resources affected by change → large blast radius requires additional approval.

Integration testing (post-apply, in test environment): 9. Terratest — Go-based tests that: apply IaC → validate infrastructure created correctly (right instance types, correct networking, proper security groups) → destroy. 10. Kitchen-Terraform — InSpec-based compliance testing post-provision. 11. Smoke tests — after IaC apply, run health checks on provisioned infrastructure.

Continuous validation: 12. Drift detection scheduled — every 15 min compare actual state with IaC state (per 82.8). 13. State backup — Terraform state backed up before every apply. 14. Lock management — state locking prevents concurrent modifications.

CI/CD integration: IaC changes follow same pipeline as application code: PR → lint + scan + policy check → plan review (human for production) → apply → post-apply validation → merge. IaC without tests is rejected in PR review.

92.4 Policy testing coverage

Status: [N] Normatywny Odbiorca: Security, DevOps, Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 82.1, 90.1, 92.1

Policy testing zapewnia, że polityki bezpieczeństwa i dostępu są poprawnie implementowane i nie zawierają luk ani niezamierzonych efektów.

Zakres: 1. OPA/Rego policies — każda polityka w Open Policy Agent ma dedykowane testy jednostkowe. Pokrycie: 100% reguł allow/deny. 2. IAM policies — role-based access control: test per rola × per zasób × per operacja. Matryca dostępu testowana automatycznie. 3. Network policies — Kubernetes NetworkPolicy, firewall rules: test per reguła (allow/deny traffic per source/destination/port). 4. HSM policies — key usage restrictions, operator permissions: test per key type × per operacja. 5. Tenant isolation policies — test per tenant: verify no cross-tenant access at network, data, and application layer.

Metodologia: - Positive testing — weryfikacja że uprawniony dostęp jest permitted. - Negative testing — weryfikacja że nieuprawniony dostęp jest denied. Krytyczne: testowanie all deny paths, nie tylko happy path. - Boundary testing — edge cases: expired tokens, revoked certificates, concurrent policy changes. - Regression testing — po każdej zmianie polityki, full test suite uruchamiany.

Coverage metrics:

Policy type	Coverage target	Measurement
OPA/Rego	100% rules	Rego test coverage tool
IAM roles	100% role×resource	Automated matrix test
Network policies	100% rules	Traffic injection test
HSM policies	100% key×operation	HSM test harness
Tenant isolation	100% tenant pairs	Cross-tenant probe test

Integration z CI/CD: Policy testy uruchamiane w pipeline (80.3) przed każdym deploy. Failure = deploy blocked. Policy change bez testów = rejected w PR review. Nowa polityka wymaga minimum: 3 positive tests, 3 negative tests, 1 boundary test.

Audit evidence: Test results przechowywane jako compliance evidence. Audytor może zweryfikować: która polityka, kiedy testowana, z jakim wynikiem, kto reviewed.

92.5 Contract testing coverage

Status: [R] Rekomendowany Odbiorca: Developers, QA, Architecture Wpływ na baseline: Średni Powiązane rozdziały: 81.1, 88.8, 92.1

Contract testing pokrywa interfejsy między serwisami SYLION, zapewniając że zmiany w jednym serwisie nie łamią oczekiwań innego.

Pokrycie:

Consumer → Provider	Kontrakt	Priority
G2 → IAM	Authentication, authorization API	Critical
G2 → Policy Engine	Policy evaluation API	Critical
Session Broker → Workload Manager	Session lifecycle API	Critical
Management Plane → All components	Config push API	High
Matrix → IAM	User sync, token validation	High
Telemetry Collector → SIEM	Event format, transport	High
Client (Thin Client) → G1	Connection protocol, handshake	Critical
Admin Portal → Management API	All admin operations	High

Metryki pokrycia: - Interaction coverage — % zdefiniowanych interakcji (request/response par) objętych kontraktem. Target: 100% dla Critical, ≥90% dla High. - State coverage — % stanów (success, error, timeout, auth failure) objętych kontraktem per interakcja. Target: ≥80%. - Version coverage — kontrakty pokrywają current version + previous version (backward compatibility).

Governance: - Nowy endpoint API wymaga kontraktu przed merge do main branch. - Breaking change (kontrakt modification) wymaga explicit consumer approval. - Contract drift detection (88.8) uruchamiany daily — detects kontrakty out of sync z implementation. - Orphaned contracts (consumer removed but contract remains) cleaned up quarterly.

Narzędzia: Pact (consumer-driven), Spring Cloud Contract (provider-driven) jako alternatywa. Pact Broker centralnie przechowuje i wersjonuje kontrakty. Can-I-Deploy check w pipeline — deploy blocked jeśli kontrakt incompatible.

Raportowanie: Dashboard z: total contracts, % verified, last verification date, breaking changes pending. Weekly report do Architecture Board.

92.6 Security control coverage

Status: [N] Normatywny Odbiorca: Security, CISO, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 90.1, 78.1, 92.1

Security control coverage mierzy, jaki procent zdefiniowanych kontroli bezpieczeństwa jest automatycznie testowany.

Kategorie kontroli i pokrycie:

Kategoria	Kontrole	Target	Metoda
Authentication	MFA, certificate auth, token validation, session expiry	100%	Automated E2E
Authorization	RBAC, tenant isolation, resource-level permissions	100%	Policy tests (92.4)
Encryption in transit	TLS 1.3, IKEv2 IPsec, PQC hybrid	100%	Protocol validation
Encryption at rest	AES-256, key management, HSM integration	100%	Crypto validation
Network segmentation	Zone isolation, firewall rules, microsegmentation	100%	Traffic injection
Logging & audit	Immutable logs, tamper detection, completeness	100%	Log verification
Vulnerability management	Patching cadence, CVE scanning, dependency audit	≥95%	SCA in pipeline
Secure development	SAST, secret scanning, license compliance	≥95%	Pipeline gates
Incident detection	IDS/IPS rules, anomaly detection, SOC alerting	≥90%	Red team / purple team
Data protection	CDR, DLP, data classification, retention	100%	Functional tests

Mapowanie do frameworków: Każda kontrola mapowana do: ISO 27001 Annex A control, NIST 800-53 control, CIS benchmark. Mapowanie pozwala na raportowanie compliance coverage per framework.

Pomiar: - Automated coverage — % kontroli z automatycznym testem w CI/CD lub scheduled test suite. - Manual coverage — % kontroli testowanych manualnie (penetration testing, audyt). Target: zmniejszanie manual na rzecz automated. - Effectiveness — % kontroli, które skutecznie blokują attack scenario (mierzone podczas red team exercises).

Gap analysis: Kwartalna analiza: które kontrole nie mają testów, które testy nie pokrywają wszystkich scenariuszy, które kontrole failed w ostatnim audycie. Gap → action item z owner i deadline. Critical gap (authentication, authorization, encryption) = P1 remediation.

Raportowanie: Monthly security control coverage report do CISO. Quarterly report do Architecture Board. Annual report do audytora zewnętrznego.

92.7 Quality gates and thresholds

Status: [N] Normatywny Odbiorca: QA, DevOps, Engineering Leads Wpływ na baseline: Krytyczny Powiązane rozdziały: 80.4, 80.6, 92.1

Quality gates to zautomatyzowane checkpoint-y w pipeline, które blokują deploy jeśli thresholds nie są spełnione.

Gate definitions:

PR Gate (every pull request): - ☐ Unit tests: 100% pass, ≥80% line coverage. - ☐ Linting: 0 errors (warnings acceptable). - ☐ SAST: 0 critical/high findings. - ☐ Secret scanning: 0 findings. - ☐ License compliance: 0 prohibited licenses. - ☐ PR review: ≥1 approval (≥2 for security-sensitive changes). Block: merge to main branch.

Build Gate (every build on main): - ☐ All PR gate criteria. - ☐ Integration tests: 100% pass. - ☐ Contract tests: 100% pass. - ☐ SCA (dependency scan): 0 critical findings, ≤5 high findings. - ☐ SBOM generated and stored. - ☐ Artifact signed with verified key. Block: artifact promotion to staging.

Staging Gate (before production deploy): - ☐ All build gate criteria. - ☐ E2E tests: 100% pass. - ☐ Performance regression: <10% degradation vs baseline. - ☐ Security regression: 0 new findings vs previous version. - ☐ IaC validation: plan approved, no unexpected changes. - ☐ Policy tests: 100% pass. Block: deployment to production.

Production Gate (during deploy): - ☐ Pre-deploy health check: target environment healthy. - ☐ Canary metrics: within SLO for 15 min observation period. - ☐ No P1/P2 incidents open in target environment. Block: full rollout (canary → full).

Override policy: Gate override requires: dual approval (SRE Lead + Security Lead), documented justification, ticket reference. Override logged in audit trail. Override for security gates (SAST, SCA) additionally requires CISO approval. No override for secret scanning or license compliance — these are absolute blockers.

Threshold review: Thresholds reviewed quarterly. Tightening thresholds (e.g., coverage 80% → 85%) requires team agreement and 30-day grace period.

CZĘŚĆ XI — MONITOROWANIE, OBSERWOWALNOŚĆ I SRE

Rozdział 93. Model obserwowalności

93.1 Logs — structured, immutable, Zone 4

Status: [N] Normatywny Odbiorca: SRE, Security, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 84.1, 93.2, 94.1

Logi SYLION są fundamentem obserwowalności i forensic capability. Wszystkie logi są strukturalne, immutable i przechowywane w Zone 4.

Zasady logowania: - Structured: JSON format z ustalonymi polami (timestamp, level, component, correlation_id, tenant_id, message, metadata). - Immutable: logi po zapisaniu nie mogą być modyfikowane ani usuwane (WORM storage). - Centralized: wszystkie logi z wszystkich komponentów agregowane w centralnym log store (Zone 4). - Encrypted: logi encrypted at rest (AES-256) i in transit (TLS 1.3). - Tenant-isolated: logi jednego tenanta niedostępne dla innego tenanta (access control na log store).

Poziomy logowania: - ERROR: błąd wymagający attention (alertowany P3+). - WARN: sytuacja niepożądana, ale system kontynuuje (monitored, nie alertowany). - INFO: significant business event (user login, session created, config changed). - DEBUG: szczegóły diagnostyczne (domyślnie wyłączone w prod, włączane dynamicznie per component).

Co NIE jest logowane: - Treści komunikacji (nigdy). - Hasła, tokeny, sekrety (nigdy — masked w logach). - Dane osobowe ponad minimum (user ID tak, imię/email tylko w audit trail z uzasadnieniem).

Retencja: - Production logs: 90 dni hot, 1 rok warm, 5 lat cold (compressed, archived). - Security/audit logs: 5 lat (STANDARD), 10 lat (STATE). - Debug logs: 7 dni (auto-deleted).

93.2 Metrics — real-time, Prometheus-compatible

Status: [N] Normatywny Odbiorca: SRE, DevOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 83.1, 93.1, 93.3

Metryki SYLION zbierane w modelu Prometheus (pull-based scraping) z 15-sekundowym interwałem.

Kategorie metryk:

Kategoria	Przykłady	Retention
Infrastructure	CPU, RAM, disk I/O, network I/O per node	15 days raw, 1 year 1-min avg, 5 years 5-min avg
Application	Request rate, error rate, latency histograms per endpoint	15 days raw, 1 year 1-min avg
Business	Active sessions, active users, messages sent, files transferred	1 year raw, indefinite daily aggregates
Security	Auth failures, policy denials, WAF blocks	1 year raw
SLI	Availability, latency P50/P95/P99, error rate	1 year raw (source of truth for SLO)

Labeling convention: - component (g1, g2, broker, workload, matrix, cdr, management). - tenant_id (per-tenant metrics isolation). - region. - environment (prod, staging, dev). - instance.

Alerting integration: Metryki → Prometheus → Alertmanager → PagerDuty/Opsgenie. Alert rules defined as code (version controlled, reviewed, tested).

93.3 Traces — distributed, OpenTelemetry

Status: [N] Normatywny Odbiorca: SRE, Developers Wpływ na baseline: Wysoki Powiązane rozdziały: 93.1, 93.2, 94.2

Distributed tracing umożliwia śledzenie requesty through cały stos SYLION.

OpenTelemetry instrumentation: Każdy komponent SYLION eksportuje traces via OpenTelemetry SDK: - Span per operation (API call, database query, HSM operation, policy evaluation). - Context propagation przez HTTP headers (W3C Trace Context) i gRPC metadata. - Automatic instrumentation dla standardowych libraries + custom instrumentation dla SYLION-specific logic.

Trace structure:

[API Request] → [Auth Check (IAM)] → [Policy Eval (OPA)] → [Session Create (Broker)] → [VM Provision (Firecracker)] → [Response]

Każdy span zawiera: start/end time, status (ok/error), attributes (component, operation, result).

Sampling: - 100% traces dla errors i slow requests (P99+). - 100% traces dla security events. - 10% traces dla normal requests (adaptive sampling — increase during investigation). - Per-tenant override (100% tracing per tenant na żądanie, max 24h).

Storage: Traces przechowywane w Jaeger/Tempo, 14 dni retention. Long-term traces (security investigations) exportowane do Zone 4.

93.4 Events — security events, business events

Status: [N] Normatywny Odbiorca: SRE, Security, Product Wpływ na baseline: Wysoki Powiązane rozdziały: 93.1, 93.5, 94.1

Events to dyskretne zdarzenia (w odróżnieniu od ciągłych metryk i logów) — reprezentują significant momenty w życiu systemu.

Taksonomia eventów:

Security events (100% sampling, Zone 4, immutable): - Authentication: login success/failure, MFA challenge, token refresh, session creation/termination. - Authorization: access granted/denied, privilege escalation attempt, policy violation. - Network: VPN tunnel up/down, IKEv2 rekey, firewall rule trigger, DDoS detection. - Data: file upload/download, CDR processing result, data export. - Configuration: security policy change, certificate change, HSM operation. - Anomaly: unusual behavior detected, IDS/IPS trigger, integrity check failure.

Infrastructure events (100% sampling for critical, adaptive for others): - Lifecycle: component start/stop/restart, microVM boot/terminate, broker assignment. - Health: health check pass/fail, degradation detected, recovery detected. - Scaling: auto-scale trigger, capacity threshold reached, resource allocation. - Deployment: deploy start/complete, rollback triggered, canary promoted.

Business events (100% sampling): - Tenant: tenant created/modified/deactivated, tier change, operator added/removed. - Session: session start/end, session quality degradation, session migration. - Communication: room created/archived (metadata only, no content), federation event. - Billing: usage milestone, quota approaching, SLA breach.

Event schema (standardized):

```
{ "event_id": "uuid", "timestamp": "ISO-8601 UTC nanosecond", "event_type": "security.auth.login_success", "severity": "info|warning|error|critical", "source": "component:instance", "tenant_id": "uuid", "correlation_id": "uuid", "actor": "user_id or system", "target": "resource affected", "outcome": "success|failure", "details": { }, "metadata": { "region": "", "zone": "" } }
```

Routing: Security events → Zone 4 + SIEM. Infrastructure events → Zone 4 + monitoring. Business events → Zone 4 + analytics. All events queryable via unified API z tenant isolation.

93.5 Security telemetry — Zone 4, SIEM

Status: [N] Normatywny Odbiorca: SOC, Security Wpływ na baseline: Krytyczny Powiązane rozdziały: 83.6, 88.6, 93.4

Security telemetry jest dedykowanym strumieniem danych bezpieczeństwa, przechowywany w Zone 4 (isolated, immutable).

Źródła: - WAF/IDS logs i alerty. - Authentication logs (all success/failure). - Authorization decisions (all deny, sample of allow). - Network flow data (aggregated, not packet captures). - HSM audit logs. - Certificate lifecycle events. - Configuration change logs. - Vulnerability scan results. - Endpoint (terminal) compliance status.

SIEM integration: Security telemetry ingestowane do SIEM w real-time. SIEM rules detect: - Brute force attempts (N auth failures from same source in time window). - Impossible travel (user login from two distant locations in short time). - Anomalous data access (user accessing resources outside normal pattern). - Policy violation patterns. - Lateral movement indicators.

Isolation: Security telemetry w Zone 4 jest oddzielony od operational telemetry. Dostęp wyłącznie dla SOC i authorized Security team. No developer access bez explicit authorization i justification.

93.6 Session telemetry — connection quality, heartbeat

Status: [N] Normatywny Odbiorca: SRE, Network Engineering, Product Wpływ na baseline: Wysoki Powiązane rozdziały: 93.2, 94.5, 88.4

Session telemetry dostarcza real-time informacji o jakości połączeń operatorów, umożliwiając proaktywne wykrywanie problemów.

Zbierane metryki per sesja:

Metryka	Granularity	Retention (hot)	Użycie
Latency (RTT)	Co 10s	7 dni	Quality monitoring
Jitter	Co 10s	7 dni	Voice/video quality
Packet loss	Co 10s	7 dni	Connection stability
Throughput (Mbps)	Co 30s	7 dni	Bandwidth monitoring
Heartbeat status	Co 10s	24h	Liveness detection
Session duration	On session end	30 dni	Usage analytics
Reconnection events	On event	30 dni	Stability tracking
Display resolution	On session start	7 dni	Performance tuning
Input latency	Co 30s	7 dni	User experience

Heartbeat mechanism: - Thin client sends heartbeat to broker co 10s. - Broker expects heartbeat within 15s (10s interval + 5s grace). - 3 consecutive missed heartbeats (45s) → session marked as disconnected → reallocation trigger (97.2). - Heartbeat contains: timestamp, session ID, client-side latency measurement, client health indicators.

Quality scoring: Composite session quality score (0–100) obliczany z ważonych metryk: - Latency <50ms: 100, 50–100ms: 80, 100–200ms: 50, >200ms: 20 (weight: 30%). - Jitter <10ms: 100, 10–30ms: 70, >30ms: 30 (weight: 20%). - Packet loss <0.1%: 100, 0.1–1%: 60, >1%: 20 (weight: 25%). - Input latency <20ms: 100, 20–50ms: 70, >50ms: 30 (weight: 25%).

Score <60 → alert do operations. Score <40 → alert do operatora + investigation. Persistent low score (>5 min) → proactive session migration suggestion.

Privacy boundary (per 94.5): Session telemetry nie zawiera: treści komunikacji, zawartości ekranu, informacji o wpisywanym tekście, odwiedzanych stronach. Wyłącznie technical quality metrics.

93.7 Tenant telemetry — per-tenant dashboards, privacy boundary

Status: [N] Normatywny Odbiorca: Account Management, Customers Wpływ na baseline: Średni Powiązane rozdziały: 83.5, 83.7, 93.6

Tenant telemetry dostarcza klientowi wgląd w jakość usługi bez ujawniania wewnętrznych szczegółów platformy.

Co tenant widzi: - Uptime / availability status. - Session count (active, total per period). - Average session quality (latency, packet loss — aggregated). - File transfers (count per period, success rate). - Active users count. - Incident history (affecting their tenant). - SLA report.

Co tenant NIE widzi: - Internal component health. - Infrastructure metrics (CPU, RAM, network — internal). - Other tenant data (izolacja — absolutna). - Security telemetry detail (tenant widzi „incident occurred and was resolved”, nie root cause internals). - Individual session details (privacy — tenant admin może widzieć aggregates, nie individual operator sessions unless explicitly configured).

Privacy boundary: Tenant telemetry jest generowana z filtrowanego widoku głównego telemetry store. Filter gwarantuje: - Only tenant_id matching data returned. - No internal system references exposed. - PII minimized (user counts, nie user names unless authorized admin).

93.8 Admin telemetry — management plane operations

Status: [N] Normatywny Odbiorca: SRE, Security, Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 80.10, 93.1, 93.4

Admin telemetry rejestruje wszystkie operacje na management plane.

Logowane operacje: - User provisioning (create, update, deactivate, delete). - Role assignment (grant, revoke). - Policy changes (create, update, delete). - Configuration changes (any config store modification). - Certificate operations (issue, renew, revoke). - Deployment operations (deploy, rollback). - Backup operations (create, restore, verify). - Access to admin interfaces (login, actions, logout).

Atrybuty: Każda operacja logowana z: who (admin user ID), what (operation type, resource), when (timestamp), where (source IP hash, session ID), outcome (success/failure), justification (jeśli required by policy).

Immutability: Admin telemetry jest immutable (Zone 4). Administratorzy nie mogą modyfikować ani usuwać logów swoich własnych operacji. To jest fundamentalne dla audit trail integrity.

Review: Weekly review admin telemetry: anomaly detection (unusual admin operations, off-hours activity, bulk operations). Quarterly audit: external auditor reviews admin telemetry.

Rozdział 94. Telemetria, sampling i korelacja zdarzeń

94.1 Sampling rules — 100% for security, adaptive for performance

Status: [N] Normatywny Odbiorca: SRE, Security Wpływ na baseline: Wysoki Powiązane rozdziały: 93.1, 93.3, 94.2

Reguły samplingu determinują, ile danych telemetrycznych jest zbieranych i przechowywanych.

Reguły:

Typ danych	Sampling rate	Uzasadnienie
Security events	100%	Zero tolerance for missing security data
Audit events	100%	Compliance requirement
Error traces	100%	Every error needs investigation capability
Slow request traces (P99+)	100%	Performance anomalies need full traces
Normal request traces	1-10% (adaptive)	Cost optimization; increase during investigation
Logs (ERROR/WARN)	100%	Important operational signals
Logs (INFO)	100%	Business events, not high volume
Logs (DEBUG)	0% default, 100% when enabled	Enabled per component for investigation (max 24h)
Metrics	100% (aggregated)	Metrics are already aggregated; no sampling needed

Adaptive sampling: Normal request trace sampling adapts based on: - Current error rate (higher error → higher sampling). - Active investigation (manual override to 100%). - Cost budget (if storage costs exceed threshold → reduce sampling to minimum).

94.2 Correlation IDs — per-request, per-session, per-incident

Status: [N] Normatywny Odbiorca: SRE, Developers Wpływ na baseline: Wysoki Powiązane rozdziały: 93.3, 94.3, 96.2

Correlation IDs umożliwiają powiązanie logów, metryk i traces dotyczących tej samej operacji.

Hierarchia correlation IDs: - Request ID: unikatowy per API request. Propagowany przez wszystkie komponenty obsługujące request. - Session ID: unikatowy per operator session. Powiązany z request IDs w ramach sesji. - Incident ID: unikatowy per incident. Powiązany z request IDs i session IDs affected. - Trace ID: OpenTelemetry trace ID. 1:1 z Request ID w prostych przypadkach; aggregated w complex flows.

Propagation: - HTTP: X-Request-ID, X-Session-ID headers + W3C traceparent header. - gRPC: metadata fields. - Message queues: message headers. - Logs: correlation_id field w JSON log entry.

Lookup: Podanie dowolnego correlation ID umożliwia znalezienie: - Wszystkich logów z tego ID. - Wszystkich traces z tego ID. - Wszystkich metryk (jeśli labeled). - Powiązanych IDs (request → session → incident).

94.3 Cross-layer correlation — terminal → G1 → G2 → workload trace

Status: [N] Normatywny Odbiorca: SRE, Security, Architecture Wpływ na baseline: Wysoki Powiązane rozdziały: 94.2, 93.3, 96.2

Cross-layer correlation umożliwia śledzenie żądania operatora przez wszystkie warstwy SYLION — od klienta do workloadu i z powrotem.

Architektura korelacji:

Operator (Thin Client) → G1 (VPN Gateway) → G2 (App Gateway) → Session Broker → Workload (microVM) trace_id: abc123 span: g1_vpn span: g2_auth span: broker_assign span: workload_exec parent: none parent: abc123 parent: g1_vpn parent: g2_auth parent: broker_assign

Implementacja: 1. Trace initiation — Thin Client generuje trace_id (OpenTelemetry W3C Trace Context format: 128-bit trace ID + 64-bit span ID). 2. G1 propagation — G1 receives packet → extracts trace context from header → creates G1 span → forwards with trace context. 3. G2 propagation — G2 receives request → extracts trace context → creates G2 span (with authentication, authorization sub-spans) → forwards. 4. Broker propagation — Session Broker receives → creates broker span

(with session assignment sub-spans) → forwards. 5. Workload propagation — Workload receives → creates workload span → processes → response propagates back through same chain.

Cross-layer visibility: Single trace view w monitoring tool (Jaeger, Tempo) pokazuje: całkowity czas operacji, czas per layer, where time was spent (bottleneck identification), errors at any layer.

Correlation enrichment: Każdy span wzbogacony o: component name, component instance ID, tenant ID, operator ID (pseudonymized), session ID, region. Enrichment umożliwia filtrowanie: „pokaż wszystkie traces dla tenant X z latency >500ms.”

Security correlation: Trace ID linkowany z security events (93.5): jeśli security alert fires, SOC może wyszukać trace zawierający pełny context operacji, która triggered alert.

Limitations: - Thin Client → G1: trace context w IPsec nie jest standardowy — custom implementation via IKEv2 Notify payload lub in-band signaling po tunnel establishment. - Performance overhead: <1% CPU per component for tracing (sampling reduces overhead per 94.1). - Privacy: trace context nie zawiera content — only structural metadata (component, timing, result).

Retention: Active traces: 24h full resolution. Aggregated traces (P50, P90, P99 per route): 30 dni. Security-flagged traces: per forensic retention policy (94.7).

94.4 Tenant-aware telemetry — isolation of tenant data

Status: [N] Normatywny Odbiorca: SRE, Security, Architecture Wpływ na baseline: Krytyczny Powiązane rozdziały: 93.7, 94.5, 90.4

Tenant-aware telemetry zapewnia, że dane telemetryczne jednego tenanta nie są dostępne dla innego, nawet w systemie monitoringu.

Isolation model:

Data isolation: 1. Każdy event/metric/trace zawiera tenant_id label. 2. Telemetry storage: per-tenant namespacing (np. separate Prometheus tenant label, separate Loki streams per tenant). 3. Query isolation: dashboards i queries automatycznie filtrowane per tenant — admin tenant A widzi TYLKO dane tenant A. 4. Cross-tenant queries: dostępne WYŁĄCZNIE dla platform operators (SYLION internal) z explicit authorization i audit logging.

Access control: 5. Tenant admin dashboard: read-only view of own tenant’s metrics, logs (non-security), session quality. 6. Platform operator dashboard: cross-tenant view, restricted to authorized roles (SRE, SOC). 7. API access: telemetry API enforces tenant isolation — API token scoped to tenant, queries outside scope → 403.

Aggregation boundary: 8. Per-tenant aggregated metrics (e.g., total sessions, average latency): tenant-visible. 9. Cross-tenant aggregated metrics (e.g., platform-wide session count): platform-operator only. 10. No individual tenant identifiable from cross-tenant aggregates (k-anonymity where applicable).

Implementation: - Prometheus: multi-tenancy via Cortex/Mimir with tenant header. - Loki: multi-tenancy via tenant ID in stream labels. - Jaeger/Tempo: tenant-tagged traces, query filter enforced at API gateway. - Grafana: data source per tenant (or filtered data source), dashboard provisioned per tenant.

Testing: - Cross-tenant query test: attempt to query tenant B’s data with tenant A’s credentials → verify denied. - Label injection test: attempt to inject false tenant_id label → verify server-side enforcement (tenant_id set by collector, not by reporting component). - Aggregation leak test: verify cross-tenant aggregates don’t reveal individual tenant data.

Compliance: Tenant telemetry isolation is GDPR requirement (separate processing per controller). Evidence of isolation required for ISO 27001 audit.

94.5 Privacy-safe telemetry — no content in telemetry, metadata only

Status: [N] Normatywny Odbiorca: Security, DPO, Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 90.7, 90.9, 94.4

Telemetria SYLION nie zawiera treści komunikacji — wyłącznie metadata operacyjna.

Zasady: 1. Zero content: żaden log, metryka, trace, event nie zawiera treści komunikacji (wiadomości, pliki, głos, wideo). 2. Minimal PII: identyfikatory (user_id, tenant_id) zamiast danych osobowych (imię, email). Wyjątek: audit trail administracyjny może zawierać admin email z uzasadnieniem. 3. IP hashing: adresy IP użytkowników hashowane w telemetry (SHA-256 z salt). Pełne IP wyłącznie w security telemetry (Zone 4, restricted access). 4. No credentials: hasła, tokeny, klucze — masked (*) w logach. Automated scanning logów pod kątem accidental credential leaks. 5. File names:** nazwy plików w CDR telemetry są hashowane (nie plaintext), chyba że konieczne dla security investigation (restricted access).

Enforcement: - Automated PII scanning logów (weekly, tool: custom regex + ML-based PII detector). - Violations → P3 security incident → code fix required (add masking). - Privacy impact assessment dla każdego nowego telemetry field.

94.6 Long-term retention vs cost — hot/warm/cold tiers

Status: [N] Normatywny Odbiorca: SRE, Finance, Compliance Wpływ na baseline: Średni Powiązane rozdziały: 93.1, 94.7, 84.6

Strategia retencji telemetrii balansuje między potrzebami operacyjnymi (szybki dostęp), compliance (długoterminowe przechowywanie) i kosztami.

Model tier storage:

Tier	Storage type	Retention	Query latency	Koszt relatywny	Dane
Hot	SSD, in-memory index	7 dni	<1s	100%	Wszystkie metryki, logi, traces
Warm	HDD, indexed	30 dni	<10s	25%	Zagregowane metryki, logi (sampled), traces (sampled)
Cold	Object storage (S3/GCS), compressed	1-7 lat	<5 min	5%	Security logs (full), compliance data, aggregates
Archive	Tape/deep archive, WORM	7+ lat	<24h	1%	Regulatory retention (GDPR, sector-specific)

Polityki per data type:

Data type	Hot	Warm	Cold	Archive
Security events (Zone 4)	7 dni	30 dni	3 lata	7 lat

Infrastructure metrics	7 dni	30 dni	1 rok	—
Distributed traces	3 dni	14 dni	90 dni	—
Session telemetry	7 dni	30 dni	90 dni	—
Audit logs	7 dni	30 dni	3 lata	7 lat
Business events	7 dni	30 dni	1 rok	3 lata

Downsampling rules: - Metryki: hot (15s resolution) → warm (1 min aggregated) → cold (5 min aggregated). - Logi: hot (full) → warm (security: full, others: sampled 10%) → cold (security: full, others: deleted). - Traces: hot (full) → warm (sampled 10% + all error/slow traces) → cold (error/slow only).

Cost optimization: - Lifecycle policies automated — data automatically migrates between tiers per schedule. - Compression: gzip for warm, zstd for cold (higher compression ratio). - Deduplication: cross-tenant log deduplication for common events (system events). - Budget alerts: monthly cost tracking per tier, alert at >20% increase.

Compliance override: Tenant-specific retention requirements (e.g., 10-year retention for healthcare) override default. Additional cost passed to tenant. Retention lock (WORM) for compliance data — cannot be shortened.

94.7 Forensic retention modes — extended retention for investigations

Status: [R] Rekomendowany Odbiorca: Security, Legal, Compliance Wpływ na baseline: Średni Powiązane rozdziały: 94.6, 96.2, 93.5

Forensic retention mode umożliwia przedłużenie retencji telemetry w związku z investigation lub legal hold.

Aktywacja: - Security incident → CISO lub Security Lead aktywuje forensic retention dla affected time window i tenant. - Legal hold → Legal department aktywuje forensic retention per legal request. - Regulatory investigation → DPO aktywuje forensic retention.

Mechanizm: - Dane w affected scope (tenant, time window, component) oznaczone jako „forensic hold”. - Dane z forensic hold nie podlegają automatic retention expiry (nie przechodzą do cold/delete). - Forensic hold ma explicit end date (set by authorizing person, max 1 year, renewable).

Access: Dane w forensic hold dostępne wyłącznie dla authorized investigators (CISO, Legal, external auditor). Access logowany. No bulk export bez authorization.

Deactivation: Po zakończeniu investigation/hold, forensic retention deactivated → dane przechodzą do normalnego retention lifecycle od momentu deactivation.

Rozdział 95. Alerting, runbooks i playbooki operacyjne

95.1 Alert taxonomy — security, availability, performance, compliance

Status: [N] Normatywny Odbiorca: SRE, SOC, DevOps Wpływ na baseline: Krytyczny Powiązane rozdziały: 83.3, 93.2, 95.2

Alerty SYLION są klasyfikowane w czterech kategoriach, każda z oddzielnym routing i response model.

Security alerts: - Authentication anomaly (brute force, impossible travel). - Authorization violation (denied access attempt). - Malware detected (CDR finding). - Certificate anomaly (unexpected cert, CT log alert). - Configuration tampering (unauthorized change detected). - Routing: SOC queue → Security team escalation.

Availability alerts: - Component health check failure. - SLO breach (error budget consumption >75%). - Region/node down. - Session creation failures > threshold. - Routing: NOC/SRE on-call → Engineering escalation.

Performance alerts: - Latency regression (P99 > 2× baseline). - Throughput degradation (< 80% baseline). - Resource exhaustion (CPU >90%, RAM >85%, Disk >80%). - Queue depth exceeding threshold. - Routing: SRE on-call → Platform Engineering escalation.

Compliance alerts: - Certificate approaching expiry (<30 days). - Secret rotation overdue. - Policy drift detected. - Backup validation failure. - Audit log integrity check failure. - Routing: SRE + Compliance team → Security team escalation.

95.2 Runbook ownership — per component, per alert type

Status: [N] Normatywny Odbiorca: SRE, Engineering Leads Wpływ na baseline: Wysoki Powiązane rozdziały: 95.3, 95.5, 83.4

Jasna własność runbooków zapewnia, że każdy alert ma zdefiniowany response path i odpowiedzialnego maintainera.

Ownership model:

Per-component ownership: Każdy major component ma designated runbook owner — zespół lub osobę odpowiedzialną za utrzymanie runbooków:

Component	Runbook Owner	Backup Owner
G1 (VPN Gateway)	Network Engineering	SRE
G2 (App Gateway)	Platform Engineering	SRE
Session Broker	Platform Engineering	SRE
Workload (Firecracker)	Platform Engineering	Security
Matrix (Communication)	Backend Engineering	SRE
IAM	Security Engineering	Backend
HSM/PKI	Security Engineering	SRE
Monitoring/Telemetry	SRE	DevOps
Management Plane	Platform Engineering	SRE
CDR Pipeline	Security Engineering	Backend

Per-alert-type ownership: Każdy alert type ma zdefiniowanego primary responder (kto pierwszy reaguje) i runbook maintainer (kto utrzymuje runbook): - Availability alerts → primary: SRE on-call → runbook: component owner. - Security alerts → primary: SOC on-call → runbook: Security Engineering. - Performance alerts → primary: SRE on-call → runbook: component owner. - Compliance alerts → primary: Security on-call → runbook: Compliance team.

Responsibilities of runbook owner: 1. Tworzenie i utrzymanie runbooka per component. 2. Aktualizacja runbooka po każdym incydencie (w ciągu 5 dni roboczych per 96.7). 3. Walidacja runbooka kwartalnie (per 95.7). 4. Onboarding nowych on-call do runbooka. 5. Review i approval zmian runbooka.

Governance: - Orphaned runbook (owner left team, component ownership changed) → automatic flagging → must be reassigned within 5 days. - Runbook without owner = P2 bug (operational risk). - Ownership review: semi-annually, during team restructuring, or after major architecture changes.

95.3 Runbooks per component

Status: [N] Normatywny Odbiorca: SRE, On-Call Engineers Wpływ na baseline: Wysoki Powiązane rozdziały: 95.2, 95.5, 97.1

Każdy major component SYLION posiada dedykowany runbook z procedurami diagnostyki i rozwiązywania problemów.

Struktura runbooka (per component):

[Component Name] Runbook ## 1. Component overview - What it does, dependencies, data flows - Architecture diagram (link) - Key metrics and dashboards (links) ## 2. Health checks - How to verify component is healthy - Health endpoint URL - Expected response - Dashboard link ## 3. Common alerts ### Alert: [Alert Name] - What it means - Severity / SLO impact - Diagnostic steps (numbered, copy-pasteable commands) - Resolution steps - Escalation criteria - Related alerts ## 4. Emergency procedures - Restart procedure - Failover procedure - Rollback procedure - Data recovery procedure ## 5. Maintenance procedures - Scaling up/down - Certificate rotation - Version upgrade - Configuration change ## 6. Contacts - Component owner - On-call rotation link - Escalation path

Wymagane runbooki: 1. G1 Gateway — VPN tunnel diagnostics, IKEv2 debugging, DPD issues, PQC handshake issues, certificate renewal. 2. G2 Gateway — authentication failures, policy engine issues, rate limiting, session routing. 3. Session Broker — session allocation failures, reallocation issues, capacity problems, heartbeat failures. 4. Workload (Firecracker) — microVM boot failures, attestation failures, resource exhaustion, isolation issues. 5. Matrix (Synapse) — federation issues, state resolution, media storage, database performance. 6. HSM/PKI — signing failures, key ceremony procedures, HSM failover, certificate lifecycle. 7. Management Plane — API issues, config distribution, tenant provisioning, dashboard issues. 8. Monitoring Stack — Prometheus/Grafana issues, SIEM connectivity, alert pipeline, log ingestion. 9. CDR Pipeline — processing failures, queue backup, false positive handling. 10. Network Infrastructure — DNS issues, load balancer, BGP/routing, firewall.

Quality criteria: Every runbook must be executable by an on-call engineer who didn't write it. All commands copy-pasteable. All links working. Tested quarterly (per 95.7).

95.4 Playbooks per incident type

Status: [N] Normatywny Odbiorca: SRE, SOC, Incident Commander Wpływ na baseline: Wysoki Powiązane rozdziały: 83.3, 95.3, 96.1

Playbooki to wyższopoziomowe procedury dla typów incydentów (w odróżnieniu od runbooków, które są per-component).

Playbook examples: 1. Region outage playbook: detection → assessment → failover decision → failover execution → customer communication → monitoring → recovery → post-mortem. 2. Security breach playbook: detection → containment → assessment → eradication → recovery → notification → post-mortem. 3. Data loss playbook: detection → scope assessment → backup identification → restore → validation → notification → post-mortem. 4. DDoS playbook: detection → traffic analysis → mitigation (WAF rules, rate limiting, upstream filtering) → monitoring → post-mortem. 5. HSM failure playbook: detection → impact assessment → failover to secondary → ceremony planning for recovery → post-mortem. 6. Mass session failure playbook: detection → root cause triage → mitigation (broker restart, scaling, config rollback) → monitoring → post-mortem.

Linking: Alert → triggers runbook (component-specific). If runbook insufficient → triggers playbook (incident-level). Playbook references relevant runbooks.

95.5 Escalation coupling — alert → runbook → escalation → playbook

Status: [N] Normatywny Odbiorca: SRE, SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 83.3, 85.7, 95.4

Coupling between alerting, runbooks, escalation, and playbooks zapewnia spójną response.

Flow:

Alert fires → On-call receives notification → Opens runbook (linked in alert) → Follows triage steps → If resolved: close alert, document resolution. If not resolved within threshold: escalate (per escalation matrix 85.7) → Incident Commander activated → Opens playbook → Coordinates response per playbook → Resolution → Post-mortem.

Implementation: - Each alert in PagerDuty/Opsgenie contains: runbook URL, escalation policy, severity. - Escalation policy in PagerDuty auto-escalates after configured timeout. - Incident Commander role auto-assigned for P1 (SRE Lead on-call). - Playbook accessed from incident management tool (e.g., incident.io, PagerDuty War Room). - Post-mortem template auto-generated from incident timeline.

Coupling matrix:

Alert severity	Runbook required?	Auto-escalation?	Playbook activation?
P1 Critical	Tak	Tak (5 min)	Tak — Incident Commander
P2 High	Tak	Tak (15 min)	Opcjonalne
P3 Medium	Tak	Nie (manual)	Nie
P4 Low	Rekomendowane	Nie	Nie

Walidacja coupling: Automatyczny test sprawdza co tydzień, że każdy alert ma przypisany runbook URL i escalation policy. Alert bez runbooka jest flagowany i musi być naprawiony w ciągu 48h. Alert bez escalation policy jest flagowany i musi być naprawiony w ciągu 24h. Testy coupling są częścią quality gate dla nowych alertów.

95.6 Human-in-the-loop vs auto-remediation

Status: [N] Normatywny Odbiorca: SRE, Security, CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 97.1, 97.8, 83.3

Decyzja co może być automatycznie remediowane, a co wymaga ludzkiej decyzji, jest krytyczna dla bezpieczeństwa i stabilności.

Auto-remediation dozwolona (bez human approval): - Restart poda/kontenera po crash (z backoff). - Restart microVM po health check failure (max 3 retry). - Przełączenie DNS failover po region failure (po 3 consecutive checks). - Automatyczne skalowanie horizontalne (w ramach pre-approved limitów). - Certificate renewal (automated via ACME/HSM, w ramach polityki). - Config rollback po detected drift (do known-good state).

Human-in-the-loop wymagane (explicit approval): - Wszelkie operacje na HSM (key ceremony, key deletion, key rotation root CA). - Restart całego klastra (>50% nodes). - Failover całego regionu (manual trigger po weryfikacji). - Tenant migration między regionami. - Emergency certificate revocation. - Zmiana security policy w produkcji. - Modyfikacja firewall rules. - Scaling beyond pre-approved limits.

Hybrid (auto z human notification): - Session reallocation po broker failure — auto, ale z natychmiastową notyfikacją. - Workload rebuild po anomaly detection — auto, ale z alert do SOC. - Block IP po IDS detection — auto z 5-min review window (SOC może revertnąć).

Guardrails dla auto-remediation (szczegóły w 97.8): - Rate limiting: max 3 auto-remediacje tego samego typu w 15 min. - Circuit breaker: po 3 nieudanych auto-remediacjach → human escalation. - Blast radius limit: auto-remediacja nie może wpłynąć na >10% tenantów jednocześnie. - Audit trail: każda auto-remediacja logowana z pełnym kontekstem.

95.7 Playbook validation — quarterly test, results documented

Status: [N] Normatywny Odbiorca: SRE, Security, Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 95.3, 95.4, 96.6

Playbooki i runbooki muszą być regularnie walidowane, aby zapewnić ich aktualność i skuteczność.

Cykl walidacji: - Miesięcznie: Automated review — sprawdzenie czy wszystkie linki w runbookach działają, czy referencje do komponentów są aktualne, czy escalation contacts istnieją. - Kwartalnie: Tabletop exercise — zespół przechodzi przez wybrany playbook bez wykonywania akcji, weryfikując logikę i kompletność. - Półrocznie: Live drill — symulowany incydent z pełnym wykonaniem playbooksa w środowisku staging. - Rocznie: Full audit — przegląd wszystkich runbooków i playbooków, usunięcie nieaktualnych, aktualizacja po zmianach architektury.

Metryki walidacji: 1. Completeness — czy playbook pokrywa wszystkie kroki od detekcji do resolution? 2. Accuracy — czy komendy, URL-e, kontakty są poprawne? 3. Timeliness — czy SLA response time jest osiągalny przy danym playbooku? 4. Clarity — czy nowy on-call engineer może wykonać playbook bez dodatkowej pomocy?

Dokumentacja wyników: Każdy test produkuje raport zawierający: datę, uczestników, scenariusz, wynik (pass/fail per krok), znalezione problemy, action items. Raporty przechowywane w Zone 4 (immutable). Action items trackowane w systemie ticketowym z deadline. Playbook bez walidacji >90 dni jest flagowany jako „stale” i wymaga natychmiastowego przeglądu.

Continuous improvement: Po każdym realnym incydencie, powiązany playbook jest przeglądany i aktualizowany w ciągu 5 dni roboczych. Zmiany wymagają review przez co najmniej jednego inżyniera, który nie brał udziału w incydencie (fresh eyes review). Wersjonowanie playbooków jest obowiązkowe — każda zmiana generuje nową wersję z changelogiem.

Rozdział 96. RCA i post-mortem

96.1 Root cause methodology — 5 whys, fishbone, fault tree

Status: [N] Normatywny Odbiorca: SRE, Engineering Leads, CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 95.4, 96.2, 96.6

Analiza przyczyn źródłowych (RCA) jest obowiązkowa dla wszystkich incydentów P1 i P2 oraz rekomendowana dla powtarzających się P3.

Metodologie:

5 Whys: Iteracyjne pytanie „dlaczego?” aż do dotarcia do przyczyny systemowej, nie tylko bezpośredniej. Stosowane jako punkt wyjścia dla każdego RCA. Przykład: „Dlaczego sesja się rozłączyła?” → „Bo broker nie odpowiadał” → „Bo health check failował” → „Bo disk full” → „Bo log rotation nie działał” → „Bo config drift po ostatnim deploy” — root cause: brak drift detection na log rotation config.

Fishbone (Ishikawa): Diagram przyczynowo-skutkowy z kategoriami: People, Process, Technology, Environment. Stosowany gdy 5 Whys daje niejednoznaczne wyniki lub gdy podejrzewana jest wieloprzyczynowość. Zespół wspólnie mapuje potencjalne przyczyny w każdej kategorii.

Fault tree analysis: Formalne drzewo logiczne (AND/OR gates) dla złożonych incydentów z wieloma contributing factors. Wymagane dla: incydentów bezpieczeństwa (data exposure, unauthorized access), incydentów z data loss, incydentów wpływających na >20% tenantów. Produkuje kwantyfikowalny model prawdopodobieństwa failure.

Wybór metodologii:

Typ incydentu	Metodologia	Uzasadnienie
Prosty availability	5 Whys	Szybki, wystarczający
Złożony multi-factor	5 Whys + Fishbone	Wieloprzyczynowość
Security incident	Fault tree + Fishbone	Formalna analiza wymagana
Recurring issue	All three	Deep systemic analysis

Timeline: RCA musi być rozpoczęte w ciągu 24h od resolution incydentu P1, 48h dla P2. Draft RCA review w ciągu 5 dni roboczych. Final RCA opublikowane w ciągu 10 dni roboczych.

96.2 Timeline reconstruction — from Zone 4 logs, correlation IDs

Status: [N] Normatywny Odbiorca: SRE, Security, Incident Commander Wpływ na baseline: Wysoki Powiązane rozdziały: 93.1, 94.2, 94.3

Rekonstrukcja timeline jest fundamentem każdego RCA — bez precyzyjnej chronologii analiza jest spekulatywna.

Źródła danych: 1. Zone 4 logs — immutable, tamper-evident, primary source of truth. Structured logs z timestampami UTC (nanosecond precision). 2. Distributed traces — OpenTelemetry traces z correlation ID, span hierarchy. 3. Metrics — Prometheus time-series data, granularity 15s dla infrastructure, 1s dla krytycznych SLI. 4. Alerting history — kiedy alert fired, kto acknowledged, kiedy escalation. 5. Chat/communication logs — Slack/Matrix incident channel (z zachowaniem prywatności operatorów). 6. Deployment logs — pipeline execution history, config changes, feature flag changes.

Proces rekonstrukcji: 1. Scope determination — określenie okna czasowego (start: pierwszy anomalny sygnał, end: resolution confirmed). 2. Data collection — wyłączenie wszystkich logów, traces, metryk z okna + 30 min buffer z obu stron. 3. Correlation — linkowanie eventów via correlation ID (request ID, session ID, incident ID — per 94.2). 4. Timeline assembly — chronologiczne ułożenie eventów z perspektywy każdego komponentu. 5. Gap identification — identyfikacja luk w danych (missing logs, gaps in traces). 6. Cross-validation — weryfikacja timeline z wieloma źródłami (log timestamps vs metric timestamps vs alert timestamps).

Format timeline:

[UTC timestamp] [Component] [Event] [Details] [Evidence link] 2026-03-15T14:22:01.003Z G2-broker-03 Health check timeout No response for 30s [log-link] 2026-03-15T14:22:31.150Z LB-region-eu Route removed G2-broker-03 removed from pool [log-link] 2026-03-15T14:22:31.500Z Session-mgr Session reallocation 15 sessions moved to broker-04 [log-link]

Immutability: Timeline i underlying evidence muszą być immutable — przechowywane w Zone 4 z integrity protection. Nie mogą być modyfikowane po publikacji RCA.

96.3 Contributing factors — technical, process, human

Status: [N] Normatywny Odbiorca: SRE, Engineering Leads, Process Owners Wpływ na baseline: Wysoki Powiązane rozdziały: 96.1, 96.4, 96.7

Contributing factors to czynniki, które nie są bezpośrednią przyczyną, ale przyczyniły się do wystąpienia lub eskalacji incydentu.

Kategorie contributing factors:

Technical factors: - Degraded monitoring (alert not firing or delayed). - Insufficient capacity headroom. - Missing circuit breaker / rate limiter. - Outdated dependency with known vulnerability. - Configuration drift from IaC state. - Insufficient test coverage for failure mode.

Process factors: - Change management bypass (emergency change without review). - Incomplete runbook (missing steps for specific scenario). - Insufficient communication during incident (silos). - Deployment during risky window (Friday evening, before holiday). - Missing or outdated documentation.

Human factors (blameless!): - Cognitive overload (too many alerts, alert fatigue). - Insufficient training for on-call engineer. - Misunderstanding of system behavior. - Handoff gap between shifts. - Time pressure leading to shortcut.

Zasady analizy: 1. Blameless culture — contributing factors opisują systemowe warunki, NIE osobiste błędy. „Engineer nie zauważył alertu” → „Alert miał niski priorytet i był zagubiony wśród 50 innych alertów w ciągu godziny (alert fatigue).” 2. Multi-causal — większość incydentów ma wiele contributing factors. Single root cause jest uproszczeniem. 3. Systemic focus — pytanie brzmi „co w systemie (technicznym lub organizacyjnym) pozwoliło na ten outcome?”, nie „kto zawinił?” 4. Actionable — każdy contributing factor musi prowadzić do concrete corrective action.

Dokumentacja: Każdy contributing factor w RCA posiada: opis, evidence (link do logu/metryki), severity of contribution (primary, secondary, enabling), corrective action (z owner i deadline).

96.4 Corrective actions — immediate, short-term, long-term

Status: [N] Normatywny Odbiorca: SRE, Engineering Leads, Management Wpływ na baseline: Wysoki Powiązane rozdziały: 96.1, 96.3, 96.5

Corrective actions to konkretne zmiany eliminujące przyczynę źródłową i contributing factors.

Kategorie czasowe:

Immediate (0–48h): Akcje podejmowane natychmiast po resolution, zanim RCA jest kompletne. Cel: zapobieżenie powtórzeniu identycznego incydentu. - Hotfix dla bezpośredniej przyczyny. - Tymczasowy workaround (z datą expiry). - Alert tuning (dodanie lub korekta alertu). - Komunikacja do affected tenants.

Short-term (1–4 tygodnie): Akcje wymagające development effort, ale niewymagające zmian architektonicznych. - Dodanie brakującego circuit breaker. - Rozszerzenie test coverage dla failure mode. - Aktualizacja runbooka/playbooka. - Config drift remediation. - Dependency update. - Capacity planning adjustment.

Long-term (1–3 miesiące): Akcje wymagające zmian architektonicznych, procesowych lub organizacyjnych. - Redesign komponentu z single point of failure. - Implementacja nowego monitoring capability. - Zmiana deployment procesu. - Training program dla on-call engineers. - Tooling improvement.

Tracking: Każdy corrective action ma: owner (person, not team), deadline, priority, status (open/in-progress/completed/won't-fix), link do RCA. Corrective actions są trackowane w systemie ticketowym (Jira, Linear) z dedykowanym tagiem „post-mortem-action.” Status review: weekly dla immediate, bi-weekly dla short-term, monthly dla long-term. Overdue corrective actions eskalowane do Engineering Lead.

Won't-fix: Akceptowalne tylko z documented reasoning i approval Engineering Lead + CISO (jeśli security-related). Documented risk acceptance wymagane.

96.5 Preventive actions — systemic improvements

Status: [R] Rekomendowany Odbiorca: SRE, Architecture, Management Wpływ na baseline: Wysoki Powiązane rozdziały: 96.4, 96.7, 97.1

Preventive actions wykraczają poza naprawę konkretnego incydentu — eliminują klasy problemów.

Różnica corrective vs preventive: - Corrective: „Dodaj circuit breaker do brokera sesji” — naprawia konkretny failure mode. - Preventive: „Wprowadź circuit breaker pattern jako wymaganie architektoniczne dla wszystkich komponentów stateful” — eliminuje klasę.

Typowe preventive actions: 1. Architectural patterns — wprowadzenie lub wymuszenie pattern (circuit breaker, bulkhead, retry with backoff) jako standard architektoniczny. 2. Testing improvements — chaos engineering program, regular failure injection, disaster recovery drills. 3. Monitoring improvements — SLO-based alerting zamiast threshold-based, reduction of alert noise. 4. Process improvements — pre-mortem reviews przed major changes, deployment freezes during high-risk periods. 5. Tooling improvements — automated drift detection, automated capacity planning, improved incident management tooling. 6. Training —

regular game days, incident response training, on-call shadowing for new engineers. 7. Organizational — on-call load balancing, review of team boundaries, knowledge sharing sessions.

Implementation: Preventive actions mają dłuższy horyzont (3–12 miesięcy) i są trackowane jako OKR lub roadmap items. Quarterly review czy preventive actions z ostatnich post-mortemów zostały zaadresowane. Metryka: „% preventive actions completed on time” — target $\geq 80\%$.

Feedback loop: Recurring incydenty (same root cause class >2 times in 6 months) automatycznie trigger review preventive actions — dlaczego previous preventive action nie zadziałał? Co wymaga wzmocnienia?

96.6 Security post-mortem — separate track, CISO involvement

Status: [N] Normatywny Odbiorca: CISO, Security, SRE, Legal Wpływ na baseline: Krytyczny Powiązane rozdziały: 90.1, 95.1, 96.1

Security incidents wymagają osobnego procesu post-mortem ze względu na wrażliwość danych, wymogi prawne i potencjalne implikacje regulacyjne.

Kiedy security post-mortem: - Każdy incydent z podejrzeniem data exposure. - Unauthorized access (nawet jeśli unsuccessful attempt, jeśli wskazuje na lukę). - Vulnerability exploitation (nawet jeśli patch was available). - Social engineering attempt (successful or unsuccessful). - Supply chain compromise indicator. - Anomalous activity flagged by SOC.

Proces: 1. Containment verification — przed rozpoczęciem post-mortem, weryfikacja że threat jest contained. 2. Evidence preservation — forensic copy of all relevant data (Zone 4 logs, system snapshots, memory dumps jeśli dostępne). 3. CISO notification — CISO informowany o security post-mortem w ciągu 1h od decision to conduct one. 4. Restricted access — security post-mortem documents dostępne tylko dla: CISO, Security Team, involved SREs, Legal (jeśli required). NIE shared broadly jak standard post-mortem. 5. Legal hold — jeśli data exposure possible, Legal triggered dla assessment of notification requirements (GDPR 72h deadline). 6. Timeline reconstruction — jak standard RCA (96.2) ale z dodatkową analizą: attack vector, attacker TTPs (if applicable), indicators of compromise (IoCs). 7. Impact assessment — jakie dane mogły być exposed, ilu tenantów affected, jaki okres. 8. Regulatory assessment — czy wymagane notification (GDPR, sector regulators, affected individuals). 9. Corrective actions — priorytetyzowane z focus na security, nie availability. 10. Lessons learned — shared z SOC i security team, selectively shared z broader engineering (after sanitization).

Dokumentacja: Security post-mortem przechowywany w Zone 4 z restricted access (role-based). Retention: minimum 7 lat (regulatory requirement). Wersja sanitized (bez szczegółów exploita) może być shared z broader engineering po approval CISO.

96.7 Cross-team learning — blameless culture, shared learnings

Status: [R] Rekomendowany Odbiorca: All Engineering, Management Wpływ na baseline: Wysoki Powiązane rozdziały: 96.1, 96.5, 95.7

Post-mortem bez shared learnings to zmarnowana okazja. Cross-team learning zapewnia, że wiedza z incydentu rozprzestrzeni się w organizacji.

Blameless culture — fundamenty: 1. Assume good faith — każdy engineer podejmował najlepszą decyzję na podstawie dostępnych informacji w danym momencie. 2. System focus — pytanie „jak system pozwolił na ten outcome?” zamiast „kto zawinił?” 3. Transparency — post-mortem opisuje CO się stało i DLACZEGO, bez cenzury. Self-censorship z obawy przed blame osłabia learnings. 4. No punishment — żaden engineer nie jest karany za honest mistakes ujawnione w post-mortem. Karanie za brak transparency — tak. 5. Leadership modeling — leadership otwarcie przyznaje się do process failures.

Mechanizmy sharing:

Post-mortem review meeting: Otwarte spotkanie (opcjonalne uczestnictwo) gdzie zespół prezentuje post-mortem. Format: 15 min prezentacja, 15 min Q&A, 15 min discussion o broader implications. Nagranie dostępne dla tych, którzy nie mogli uczestniczyć.

Post-mortem digest: Tygodniowy lub dwutygodniowy newsletter z podsumowaniem recent post-mortemów: co się stało, co zmieniliśmy, czego się nauczyliśmy. Krótki format (3–5 zdań per post-mortem).

Runbook/playbook updates: Każdy post-mortem produkuje updates do relevant runbooków (95.3, 95.4). Updates linkowane do post-mortem source.

Pattern library: Zbiór recurring patterns z post-mortemów: „top 10 failure modes in SYLION,” „common contributing factors.” Aktualizowany kwartalnie. Używany w onboardingu nowych inżynierów i w pre-mortem reviews.

Metryki kultury: - Czas od resolution do opublikowania post-mortem (target: <10 dni roboczych). - % incydentów P1/P2 z opublikowanym post-mortem (target: 100%). - % corrective actions completed on time (target: $\geq 80\%$). - Uczestnictwo w post-mortem review meetings (tracking, nie target — wymuszone uczestnictwo szkodzi kulturze).

Rozdział 97. Self-healing i automatyczne remediacje

97.1 Restart patterns — crash-loop detection, restart with backoff

Status: [N] Normatywny Odbiorca: SRE, DevOps Wpływ na baseline: Wysoki Powiązane rozdziały: 95.6, 97.8, 83.3

Automatyczne restarty są pierwszą linią self-healing, ale wymagają inteligentnego podejścia, aby nie zamaskować root cause ani nie pogorszyć sytuacji.

Restart policy:

Pod/container restart (Kubernetes): - Default: restartPolicy=Always z exponential backoff (10s, 20s, 40s, 80s, 160s, max 5min). - CrashLoopBackOff detection: po 5 restartach w 10 min, alert P3 fires. Po 10 restartach w 30 min — P2. - Container z OOMKilled: restart + alert + metric. Recurring OOMKill (>3 in 1h) → P2 alert + investigation.

MicroVM restart (Firecracker): - Health check failure (HTTP health endpoint, 3 consecutive failures $\times$ 10s interval = 30s detection). - Restart attempt: snapshot restore jeśli dostępny ($<5s$), cold start jeśli nie ($<1s$ Firecracker boot + app init). - Max 3 restart attempts per microVM per 15 min. Po 3 failures → alert P2 + session reallocation (97.2). - Post-restart validation: health check must pass within 30s, else counted as failed restart.

Service restart (systemd): - Restart=on-failure, RestartSec=5s, StartLimitBurst=5, StartLimitIntervalSec=60s. - Po StartLimitBurst → service enters failed state → alert P2.

Idempotency requirement: Każdy komponent musi być safe to restart — restart nie może powodować: data corruption, duplicate processing, orphaned sessions, inconsistent state. Testy restart safety są częścią integration test suite (88.x).

Logging: Każdy restart logowany z: reason (health check fail, OOMKill, crash, manual), attempt number, duration, outcome (success/fail). Restarty są metryką — trending up indicates systemic issue.

97.2 Session reallocation — broker failover, session migration

Status: [N] Normatywny Odbiorca: SRE, DevOps, Architecture Wpływ na baseline: Krytyczny Powiązane rozdziały: 79.5, 84.3, 97.1

Session reallocation jest krytycznym mechanizmem self-healing — zapewnia ciągłość pracy operatora mimo awarii brokera lub workloadu.

Trigger conditions: 1. Broker health check failure — broker nie odpowiada na 3 consecutive health checks (30s detection). 2. Broker overload — CPU >90% lub memory >85% przez >5 min. 3. Region degradation — significant degradation w regionie (>30% packet loss, >500ms latency). 4. Manual evacuation — operator lub automation zarządza evacuation dla maintenance.

Reallocation process: 1. Detection (0–30s) — health check / metric threshold breach detected. 2. Session inventory (0–5s) — session manager pobiera listę aktywnych sesji na affected broker/workload. 3. Target selection (0–5s) — selection of target broker/workload based on: capacity, proximity (same region preferred), current load, affinity rules (tenant isolation). 4. Session migration (5–30s per session) — state transfer: session context, clipboard state, display state. For stateless sessions: simple reconnect to new target. 5. Client reconnect (1–5s) — thin client receives new connection endpoint, reconnects. User experience: brief interruption (1–5s), similar to network glitch. 6. Validation (0–10s) — session health check on new target, confirmation to session manager.

SLA targets: - Detection → reallocation complete: <60s dla PRO, <30s dla STATE. - User-perceived interruption: <10s (brief screen freeze, auto-reconnect). - Zero data loss (session state preserved).

Graceful vs ungraceful: - Graceful (planned maintenance): drain sessions gradually, 0 user impact. - Ungraceful (broker crash): immediate reallocation, brief user interruption.

Capacity planning: System musi utrzymywać headroom capacity dla session reallocation: N+1 minimum (utrata jednego brokera nie powoduje overload na remaining). Dla STATE tier: N+2 (utrata dwóch brokerów obsługiwalna).

97.3 Broker recreation — automated rebuild from IaC

Status: [N] Normatywny Odbiorca: SRE, DevOps Wpływ na baseline: Wysoki Powiązane rozdziały: 79.4, 80.1, 97.1

Po session reallocation (97.2), broker powinien być automatycznie odtworzony z IaC, nie naprawiany ręcznie.

Philosophy: cattle not pets. Brokery są cattle — każdy jest identyczny, provisionowany z IaC, nie ma unikalnego stanu. Awaria brokera → destroy + recreate, nigdy debug + repair.

Automated rebuild flow: 1. Health check failure detected → sessions reallocated (97.2). 2. Broker marked for destruction — removed from load balancer, DNS, service discovery. 3. State cleanup — ephemeral state discarded. Persistent state (jeśli jakikolwiek) already replicated. 4. Destroy — VM/container terminated, resources released. 5. Provision new — IaC (Terraform/Pulumi) provisions new broker instance from latest known-good artifact. 6. Configuration — Ansible/cloud-init applies configuration from versioned config store. 7. Validation — health check, smoke tests, security validation. 8. Registration — new broker registered in load balancer, DNS, service discovery. 9. Ready for sessions — broker available for new session allocation.

Timeline: - Total rebuild: <5 min (Firecracker microVM: <30s provision, <2 min full config + validation). - Full pipeline: detection → rebuild → ready: <10 min.

Guardrails: - Max 2 concurrent rebuilds per region (prevent thundering herd). - Rebuild only from known-good artifact (last promoted version, not latest build). - Post-rebuild validation must pass before broker accepts sessions. - Alert jeśli rebuild frequency >3 per hour per region (indicates systemic issue, not individual failure).

IaC consistency: Rebuilt broker musi być identyczny z innymi brokerami — same artifact version, same config version. Drift detection (82.8) runs immediately after rebuild to verify.

97.4 Workload rebuild — automatic on anomaly or health failure

Status: [N] Normatywny Odbiorca: SRE, DevOps, Security Wpływ na baseline: Wysoki Powiązane rozdziały: 79.4, 90.4, 97.3

Workloady (microVM per operator) podlegają automatycznemu rebuild przy wykryciu anomalii lub health failure.

Trigger conditions: 1. Health check failure — workload health endpoint nie odpowiada ($3 \times 10s = 30s$ detection). 2. Anomaly detection — behavioral anomaly flagged by monitoring (unusual syscalls, unexpected network connections, memory patterns inconsistent with normal operation). 3. Security alert — IDS/IPS trigger, integrity check failure, attestation failure (SEV-SNP/TDX). 4. Resource exhaustion — disk full, memory leak detected, CPU stuck at 100%. 5. Scheduled refresh — proactive rebuild per policy (e.g., every 24h for STATE tier — fresh workload daily).

Rebuild process: 1. Session save — if possible, session state saved (clipboard, open documents state). 2. Workload termination — microVM terminated (Firecracker: <100ms). 3. Forensic snapshot (only for security triggers) — memory dump and disk snapshot preserved for investigation before destruction. 4. New microVM boot — from immutable base image (Firecracker: <1s boot). 5. Configuration injection — operator-specific config, session context, policies. 6. Session restore — operator reconnected to fresh workload, session state restored. 7. Validation — health check, attestation verification, security baseline check.

User impact: - Health failure: 5–15s interruption (similar to network reconnect). - Anomaly/security: potentially longer (forensic snapshot adds 10–30s). - Scheduled refresh: can be done during operator inactive period (night, configurable).

Immutable workloads: Workloady nie mają mutable state poza sesją — base image jest immutable, config injected at boot. Rebuild = identical fresh workload. To jest fundamentalna architektura SYLION (Firecracker + immutable images).

STATE tier specifics: - TEE attestation (AMD SEV-SNP / Intel TDX) verified at every boot. - If attestation fails → workload NOT started, alert P1 to SOC. - Daily proactive rebuild ensures no persistent compromise possible.

97.5 Route failover — DNS-based, BGP-based

Status: [N] Normatywny Odbiorca: SRE, Network Engineering Wpływ na baseline: Krytyczny Powiązane rozdziały: 79.5, 84.4, 83.1

Route failover zapewnia ciągłość połączeń przy awarii regionu lub ścieżki sieciowej.

Mechanizmy:

DNS-based failover: - Health check-driven DNS (AWS Route 53 / Cloudflare / equivalent). - Active health checks co 10s na primary endpoint. - 3 consecutive failures → DNS record updated to secondary endpoint. - TTL: 60s (compromise between failover speed and DNS load). - Total failover time: detection (30s) + DNS propagation (60-120s) = 90-150s. - Use case: region failover, datacenter failover.

BGP-based failover: - Anycast routing — same IP announced from multiple locations. - BGP health check: withdraw announcement on failure. - Failover time: BGP convergence (30-90s depending on network). - Use case: DDoS mitigation (traffic rerouting), multi-provider failover.

Application-level failover: - Client-side retry logic: thin client ma listę alternative endpoints. - After connection timeout (configurable, default 10s), client tries next endpoint. - Fastest failover: <15s (client-side, no DNS dependency). - Use case: individual broker/gateway failure.

Per-tier strategy:

Tier	Primary	Secondary	Failover target
STANDARD	DNS failover	Client retry	<3 min
PRO	DNS + client retry	BGP anycast	<90s
STATE	All three layers	Active-active	<30s

Testing: Route failover testowane w staging monthly, w produkcji quarterly (controlled failover). Failover time mierzony end-to-end: od failure injection do session restoration.

Limitations: - DNS failover depends on client DNS cache — cached records may delay failover. - BGP failover may cause brief asymmetric routing. - Cross-region failover may increase latency (user ↔ further region). - Data replication lag (per 84.4) may cause stale data access during failover.

97.6 Config rollback — detected drift → automatic rollback

Status: [N] Normatywny Odbiorca: SRE, DevOps, Security Wpływ na baseline: Wysoki Powiązane rozdziały: 82.8, 80.9, 97.8

Automatyczny config rollback zapewnia, że drift od known-good configuration jest natychmiast korygowany.

Detection: - Continuous drift detection (per 82.8) — co 5 min porównanie actual config z desired state w config store. - Event-driven detection — webhook on config change triggers immediate comparison. - Startup detection — component at boot verifies config against config store.

Rollback trigger criteria: Nie każdy drift wymaga automatycznego rollback — only drifts classified as: 1. Security-critical — firewall rules, TLS config, authentication config, HSM config → automatic rollback, P1 alert. 2. Operational-critical — health check config, load balancer config, DNS config → automatic rollback, P2 alert. 3. Non-critical — logging verbosity, feature flags → alert only, manual review.

Rollback process: 1. Drift detected → classified (security/operational/non-critical). 2. For auto-rollback: retrieve last known-good config version from versioned config store. 3. Apply known-good config via same mechanism as normal config deploy (Ansible, API call, config reload). 4. Validate: drift detection re-runs immediately, confirms resolution. 5. Alert: notification to on-call with details: what drifted, from what to what, when, rollback result. 6. Investigation: ticket auto-created for root cause of drift (was it unauthorized change? buggy automation? race condition?).

Known-good state: Known-good config = last config version that was explicitly deployed via CI/CD pipeline and passed all validation gates. Manual changes to production config are prohibited (per 82.1) — any detected manual change is by definition drift.

Guardrails: - Rollback applies same config that was validated — nie older arbitrary version. - Max 3 auto-rollbacks per component per hour — beyond that, human investigation required. - Config rollback is atomic per component — partial rollback nie jest dozwolony. - Full audit trail: who/what caused drift, when detected, rollback action, result.

97.7 Limits of self-healing — what cannot be automated

Status: [N] Normatywny Odbiorca: SRE, Architecture, Management Wpływ na baseline: Wysoki Powiązane rozdziały: 95.6, 97.8, 84.7

Self-healing ma granice — automatyzacja remediacji nie jest panaceum i pewne sytuacje wymagają ludzkiej interwencji.

Scenariusze wymagające human intervention:

Data integrity issues: - Podejrzenie data corruption — wymaga ludzkiej weryfikacji zakresu i decyzji o restore strategy. - Inconsistency between replicas — automatic resolution może wybrać wrong source of truth. - Backup restore decision — which point-in-time, co z transactions between backup and failure?

Security incidents: - Active attacker w systemie — automated response może alertować atakującego o detekcji. - Zero-day exploitation — brak known-good remediation, wymaga human analysis. - Supply chain compromise — scope unknown, automated response may be insufficient. - HSM compromise indicators — wymaga physical inspection i key ceremony.

Business decisions: - Extended outage affecting SLA — decision to invoke DR vs wait for recovery jest business decision. - Tenant data migration — wymaga tenant consent i coordination. - Service degradation prioritization — which tenants/features to prioritize during partial outage.

Infrastructure limits: - Hardware failure (disk, network card, server) — wymaga physical intervention lub cloud provider ticket. - Provider outage — beyond SYLION control, human coordination with provider required. - Capacity exhaustion across all regions — scaling requires procurement/provisioning decisions.

Cascading failures: - When self-healing actions cause cascading effects (restart storm, thundering herd). - When multiple components fail simultaneously — automated systems may conflict. - When blast radius exceeds safety guards (97.8) — human must assess and authorize broader action.

Principle: Self-healing handles known failure modes with known remediations. Unknown failure modes, ambiguous situations, and decisions requiring business context require human judgment. Lepiej eskalować za wcześnie niż za późno — false escalation cost jest niski, missed escalation cost może być katastrofalny.

97.8 Safety guards for automation — circuit breakers, rate limits, human approval

Status: [N] Normatywny Odbiorca: SRE, Architecture, CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 95.6, 97.1, 97.7

Safety guards zapobiegają sytuacji, w której automation pogarsza sytuację zamiast ją poprawić.

Circuit breakers: Każdy auto-remediation mechanism ma circuit breaker, który zatrzymuje automation po threshold failures:

Mechanism	Circuit breaker threshold	Reset
Pod restart	5 restarts / 10 min	Manual reset lub 30 min cooldown
MicroVM restart	3 restarts / 15 min	Manual reset lub 60 min cooldown
Broker rebuild	3 rebuilds / hour / region	Manual reset
Session reallocation	100 sessions / 5 min / broker	Manual reset
Config rollback	3 rollbacks / hour / component	Manual reset
Route failover	2 failovers / hour / region	Manual reset

Po circuit breaker trigger: alert P1 do on-call, automation paused, human must investigate i explicitly re-enable.

Rate limits: Automation rate limits zapobiegają thundering herd: - Max concurrent rebuilds: 2 per region. - Max concurrent session reallocations: 20% total sessions per 5 min window. - Max concurrent config rollbacks: 1 per component type. - Max auto-scaling: +25% capacity per 5 min (prevent cost explosion).

Blast radius limits: Automation nie może wpływać na więcej niż: - 10% tenantów jednocześnie (per automated action). - 25% infrastructure w regionie (per automated action). - 1 region (cross-region actions require human approval).

Przekroczenie → automation paused → human approval required.

Human approval gates: Oprócz blast radius, explicit human approval wymagane dla: - Any action on HSM (key operations, config changes). - Tenant-facing config changes. - Security policy modifications. - Actions during active security incident. - DR activation (full region failover).

Audit trail: Każda automated action logowana z: timestamp, trigger (alert/metric/schedule), action taken, result, blast radius (how many tenants/components affected), safety guard status (within limits / approaching limits). Logi w Zone 4, immutable, retained minimum 1 rok.

Testing safety guards: Safety guards muszą być testowane (per 95.7): co kwartał symulacja scenariusza, w którym automation podejmuje zbyt wiele akcji — weryfikacja że circuit breakers i rate limits działają poprawnie. Broken safety guard to P1 bug.

Koniec Części XI — Monitorowanie, Obserwowalność i SRE

Podsumowanie Części VIII–XI: Rozdziały 72–97 definiują strategię odporności postkwantowej SYLION (algorytmy, migracja, HSM, walidacja), pełny model operacyjny (wdrożenia, CI/CD, konfiguracja, monitoring, backup, support), strategię testowania (E2E, integracyjne, wydajnościowe, bezpieczeństwa, akceptacja), oraz zaawansowane praktyki SRE (obserwowalność, telemetria, alerting, RCA, self-healing). Całość stanowi spójny framework operacyjny zapewniający bezpieczeństwo, ciągłość i zarządzalność systemu SYLION na każdym tierze. # KSIĘGA SYSTEMU SYLION 3.0

CZĘŚĆ XII — INCYDENTY, FORENSICS I REAGOWANIE

Rozdział 98. Proces zarządzania incydentami

Status: [N] Normatywny Odbiorca: SOC, IR Team, Administratorzy, CISO, Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 99, 100, 101, 102, 42, 55

98.1 Definicja incydentu

W kontekście platformy SYLION incydent bezpieczeństwa definiowany jest jako każde zdarzenie, które narusza lub zagraża poufności, integralności, dostępności lub rozliczalności systemu, jego komponentów lub przetwarzanych danych. Klasyfikacja zdarzeń w SYLION musi uwzględniać trzy odrębne kategorie:

Incydenty bezpieczeństwa (Security Events): Obejmują nieautoryzowany dostęp do komponentów infrastruktury (G1, G2, session broker, workloady), próby kompromitacji terminali lub routerów, naruszenie polityk Zero Trust, anomalie w logach Zone 4, próby exfiltracji danych przez CDR lub kanały boczne, kompromitację kluczy kryptograficznych w HSM/PKI, oraz wszelkie naruszenia integralności hash chain w logach immutable. Każde zdarzenie wykryte przez SIEM korelujące z wzorcami znanych ataków musi być traktowane jako potencjalny incydent bezpieczeństwa.

Incydenty dostępności (Availability Events): Obejmują awarię regionu, degradację usług session brokera, niedostępność workloadów microVM, awarię replikacji Matrix homeserver, utratę łączności IPsec IKEv2, oraz każdą sytuację skutkującą przerwaniem ciągłości sesji operatorów. Incydenty dostępności mogą eskalować do incydentów bezpieczeństwa, jeśli degradacja wpływa na funkcje ochronne (np. awaria SIEM, utrata logowania do Zone 4).

Incydenty compliance (Compliance Events): Obejmują naruszenie procedur dual authorization, nieautoryzowane użycie break-glass, przekroczenie terminów retencji danych, naruszenie warunków umownych z klientem dotyczących rezydencji danych, oraz wszelkie zdarzenia mogące skutkować obowiązkiem notyfikacji regulatora (GDPR Art. 33, NIS2).

Rozróżnienie alert vs incydent vs problem: - Alert — automatyczne powiadomienie generowane przez SIEM, monitoring lub system detekcji anomalii. Alert sam w sobie nie jest incydem; wymaga oceny (triage). - Incydent — zdarzenie potwierdzone przez analityka SOC jako wymagające reakcji. Ma przypisaną severity, właściciela i timeline. - Problem — powtarzający się wzorec incydentów wskazujący na systemową przyczynę wymagającą zmiany architektonicznej lub proceduralnej. Problemy są eskalowane do feed-back loop (Rozdział 102).

98.2 Triage

Proces triage stanowi krytyczny etap między detekcją a formalnym otwarciem incydentu. W SYLION triage musi być przeprowadzony przez analityka SOC poziomu L2 lub wyższego, posiadającego aktualną certyfikację wewnętrzną (Rozdział 105.3).

Kto przeprowadza triage: - L1 SOC — wstępna ocena alertu, filtrowanie false positives, eskalacja do L2 - L2 SOC — formalna klasyfikacja severity, otwarcie incydentu w systemie zarządzania, przypisanie Incident Managera - L3 SOC / IR Team — triage złożonych incydentów wymagających wiedzy architektonicznej (G1/G2, HSM, Confidential Computing)

Kryteria oceny severity przy triage: 1. Czy dane operatorów są zagrożone? 2. Czy integralność infrastruktury jest naruszona? 3. Czy usługa jest niedostępna? 4. Ile operatorów/klientów jest dotkniętych? 5. Czy istnieje aktywny wektor ataku? 6. Czy incydent wymaga notyfikacji regulatora?

SLA na czas triage:

Priorytet	Czas na triage	Warunek
P1 (Critical)	5 minut	Aktywne naruszenie, dane zagrożone
P2 (High)	15 minut	Potencjalne naruszenie, degradacja
P3 (Medium)	1 godzina	Anomalia, sytuacja kontrolowana
P4 (Low)	4 godziny	Informacyjne, brak bezpośredniego ryzyka

Czas triage mierzony jest od momentu wygenerowania alertu do momentu formalnej klasyfikacji i otwarcia incydentu. W przypadku przekroczenia SLA, system automatycznie eskaluje alert do kolejnego poziomu SOC.

98.3 Model severity

Model severity w SYLION opiera się na czterostopniowej skali priorytetów, z jasno zdefiniowanymi kryteriami kwalifikacji i wymaganymi czasami reakcji:

P1 — Critical (Krytyczny): - Aktywna kompromitacja infrastruktury (G1, G2, session broker, Matrix homeserver) - Potwierdzony wyciek danych operatorów lub klientów - Kompromitacja kluczy kryptograficznych HSM - Naruszenie integralności Zone 4 (hash chain broken) - Utrata kontroli nad komponentem infrastruktury - Czas reakcji: Natychmiastowa mobilizacja IR Team (24/7), containment w ciągu 15 minut, Incident Commander wyznaczony w ciągu 5 minut - Eskalacja: Automatyczna notyfikacja CISO, CTO, CEO. Kryzysowy pokój Matrix aktywowany.

P2 — High (Wysoki): - Podejrzenie kompromitacji niepotwierdzonych jeszcze dowodami exfiltracji - Degradacja usługi wpływająca na więcej niż 20% operatorów - Anomalia w logach wskazująca na aktywny rekonesans - Podejrzenie supply chain compromise - Niepowodzenie dual authorization z jednoczesną anomalią admin activity - Czas reakcji: IR Team w ciągu 30 minut, containment w ciągu 1 godziny - Eskalacja: CISO + zespół zarządzający powiadomieni w ciągu 1 godziny

P3 — Medium (Średni): - Izolowana anomalia w jednym komponencie, brak eskalacji - Pojedyncza utrata terminala lub routera (bez oznak kompromitacji) - Przejściowa degradacja jednego regionu z automatycznym failover - Alert SIEM korelujący z niskim confidence score - Czas reakcji: Analiza w ciągu 4 godzin, plan działania w ciągu 8 godzin - Eskalacja: SOC Manager powiadomiony, raport statusowy co 4 godziny

P4 — Low (Informacyjny): - Alert informacyjny bez bezpośredniego wpływu na bezpieczeństwo - Planowane audyty compliance wykrywające drobne niezgodności - Pojedyncze failed login attempts nieprzekraczające progu alertu - Czas reakcji: Ocena w ciągu 24 godzin - Eskalacja: Zapis w tickecie, przegląd na następnym daily standup

98.4 Containment

Containment w SYLION realizowany jest zgodnie z zasadą „destroy and rebuild” — nie „patch and continue”. Infrastruktura jest niemodyfikowalna (immutable), co oznacza, że skompromitowany komponent musi zostać zniszczony i odtworzony z known-good state, nie naprawiany in-place.

Natychmiastowe działania containment per typ komponentu:

Terminal skompromitowany: - Natychmiastowe unieważnienie sesji operatora (session revoke) - Zablokowanie tokenu uwierzytelniającego terminala w IAM - Terminal nie przechowuje danych — seizure terminala nie stanowi zagrożenia dla poufności danych - Powiadomienie operatora alternatywnym kanałem o konieczności re-enrollment

Router skompromitowany: - Unieważnienie konfiguracji routera w management plane - Zablokowanie IPsec SA powiązanego z routerem - Aktywacja kill switch (jeśli router jest online) - Wygenerowanie nowej konfiguracji dla replacement routera

G1 — skompromitowany: - Natychmiastowa aktualizacja ACL — odcięcie podejrzanego G1 od sieci - Przekierowanie ruchu na backup G1 (jeśli dostępny) - Zamrożenie (freeze) wszystkich sesji przechodzących przez skompromitowany G1 - Rewokacja certyfikatów G1

G2 — skompromitowany: - Natychmiastowe przełączenie policy engine na backup G2 - Zamrożenie zmian polityk (policy freeze) — żadne modyfikacje polityk niedopuszczalne do zakończenia śledztwa - Audit trail G2 zabezpieczony w Zone 4

Workload — skompromitowany: - Natychmiastowe zniszczenie microVM operatora (destroy, nie shutdown) - Izolacja operatora od pozostałych workloadów (network isolation) - Zabezpieczenie memory snapshot (jeśli AMD SEV-SNP/TDX pozwala na forensic capture bez naruszenia poufności)

Session broker — skompromitowany: - Natychmiastowe unieważnienie wszystkich aktywnych sesji - Przełączenie na backup session broker - Rotacja kluczy sesyjnych

Izolacja operatora: W przypadku podejrzenia, że konto operatora zostało skompromitowane, musi nastąpić natychmiastowa izolacja: unieważnienie sesji, zablokowanie FIDO2 tokena, zamrożenie workloadu. Re-enrollment możliwy wyłącznie po procedurze sealed recovery key z dual authorization i 15-minutowym oknem czasowym.

98.5 Eradication

Eradykacja w SYLION polega na całkowitym usunięciu przyczyny incydentu i odtworzeniu infrastruktury z zaufanego stanu (known-good state). Nie stosuje się łatania (patching) skompromitowanych komponentów — obowiązuje zasada „zniszczyć i odbudować”.

Procedura eradykacji per typ incydentu:

Kompromitacja workloadu: 1. Zniszczenie skompromitowanej microVM (Firecracker destroy) 2. Odtworzenie microVM z czystego obrazu (verified image hash) 3. Ponowne provisioning środowiska operatora z IAM 4. Weryfikacja integralności nowego workloadu przed przywróceniem sesji

Kompromitacja komponentu infrastruktury (G1/G2/broker): 1. Deprovisioning skompromitowanej instancji 2. Rotacja wszystkich credentials powiązanych z komponentem (certyfikaty, klucze API, tokeny) 3. Deploy nowej instancji z verified image 4. Weryfikacja konfiguracji przez second-pair-of-eyes (dual authorization) 5. Przywrócenie do produkcji po testach integralności

Kompromitacja łańcucha dostaw (supply chain): 1. Identyfikacja dotkniętych artefaktów (images, dependencies, firmware) 2. Izolacja wszystkich komponentów korzystających z dotkniętych artefaktów 3. Audyt build pipeline od source code do deployment 4. Odbudowa artefaktów z zaufanych źródeł 5. Rotacja wszystkich credentials, które mogły być narażone 6. Wdrożenie dodatkowych kontroli SBOM/SLSA

Rotacja credentials: Po każdym incydencie klasy P1 lub P2, obowiązkowa jest rotacja: - Certyfikatów komponentów dotkniętych incydem - Kluczy API management plane - Tokenów sesyjnych (natychmiastowe unieważnienie + regeneracja) - W przypadku podejrzenia kompromitacji HSM — procedura emergency key ceremony

98.6 Recovery

Recovery (odtworzenie) polega na przywróceniu systemu do pełnej operacyjności z potwierdzonego stanu zaufanego. W SYLION odtworzenie musi przejść przez formalny proces weryfikacji zanim usługa zostanie przywrócona operatorom.

Procedura recovery:

Restore z known-good state: Każdy komponent odtwarzany jest z weryfikowalnego obrazu (hash match against golden image registry). Nie stosuje się odtwarzania z backupów, jeśli istnieje podejrzenie, że backup mógł zostać zatruty.

Verification testing: Przed przywróceniem do produkcji, każdy odtworzony komponent musi przejść:

Test integralności (hash verification)

Test funkcjonalny (end-to-end session establishment)

Test bezpieczeństwa (vulnerability scan, config compliance check)

Test łączności (IPsec SA establishment, Matrix federation test)

Gradual return to service: Przywracanie usługi odbywa się etapowo:

Faza 1: Przywrócenie infrastruktury bazowej (G1/G2, session broker)

Faza 2: Przywrócenie workloadów dla wewnętrznego zespołu testowego (canary)

Faza 3: Przywrócenie workloadów dla 10% operatorów (pilot)

Faza 4: Pełne przywrócenie po potwierdzeniu stabilności (minimum 1 godzina bez anomalii dla P1, 30 minut dla P2)

Monitoring wzmożniony: Po recovery, przez 72 godziny obowiązuje wzmożniony monitoring:

Obniżone progi alertów SIEM

Dodatkowe logowanie na komponentach dotkniętych incydemtem

Dedykowany analityk SOC monitorujący odtworzone komponenty

Rollback plan: Na każdym etapie recovery musi istnieć możliwość natychmiastowego rollbacku do stanu sprzed przywrócenia. Rollback trigger definiowany jest w playbooku incydentu.

98.7 Closure

Formalne zamknięcie incydentu wymaga spełnienia następujących warunków:

Wymagania dokumentacyjne: - Kompletny raport incydentowy (struktura opisana w 101.6) - Timeline incydentu z dokładnością do minuty - Lista wszystkich podjętych działań z przypisaniem osoby odpowiedzialnej - Analiza root cause (RCA) — obowiązkowa dla P1 i P2, rekomendowana dla P3 - Lista action items z feed-back loop (Rozdział 102)

Trigger lessons learned: Każdy incydent P1 musi mieć sesję lessons learned w ciągu 5 dni roboczych od zamknięcia. Incydenty P2 — w ciągu 10 dni roboczych. Sesja lessons learned prowadzona jest w formacie blame-free i musi obejmować: - Co zadziało dobrze? - Co nie zadziało? - Jakie zmiany są rekomendowane (architektura, procedury, szkolenia)? - Jakie playbooks wymagają aktualizacji?

Stakeholder sign-off: - P1: CISO + CTO + Incident Commander - P2: CISO + Incident Commander - P3: SOC Manager - P4: SOC Analyst (L2+)

Evidence packaging for compliance: Wszystkie dowody zebrane podczas incydentu muszą zostać spakowane w tamper-evident archive (hash chain + podpis cyfrowy) i zdeponowane w Zone 4 z retencją zgodną z wymogami regulacyjnymi (minimum 5 lat dla incydentów compliance, 3 lata dla pozostałych). Paczka dowodowa musi zawierać: - Logi Zone 4 z okresu incydentu - Snapshoty konfiguracji komponentów - Komunikację kryzysową (logi Matrix z crisis room) - Decyzje i autoryzacje (dual auth records) - Raport końcowy z RCA

98.8 Reporting

Raportowanie incydentów w SYLION realizowane jest na trzech poziomach:

Raportowanie wewnętrzne: Każdy incydent musi mieć kompletny raport wewnętrzny zawierający: - Timeline (dokładność co do minuty): detection → triage → containment → eradication → recovery → closure - Podjęte działania z przypisaniem osób - Wpływ na operatorów i klientów (liczba dotkniętych, czas niedostępności) - Root cause analysis - Rekomendacje i action items Raporty wewnętrzne przechowywane są w Zone 4 z retencją 5 lat.

Raportowanie do klienta: Klienci dotkniętych incydemtem muszą otrzymać komunikację zawierającą: - Co się wydarzyło — opis incydentu w języku zrozumiałym dla klienta, bez szczegółów technicznych mogących ujawnić wektory ataku - Kiedy — timeline z perspektywy klienta (kiedy wystąpił wpływ, kiedy przywrócono usługę) - Jaki wpływ — co konkretnie było niedostępne lub zagrożone - Jakie działania podjęto — ogólny opis containment i recovery - Jakie kroki zapobiegawcze — co zostanie zmienione, aby zapobiec powtórzeniu Cadence notyfikacji klientów: P1 — co 1 godzinę do rozwiązania, P2 — co 4 godziny, P3/P4 — raport podsumowujący.

Raportowanie regulacyjne: - GDPR Art. 33: W przypadku naruszenia ochrony danych osobowych — notyfikacja do właściwego organu nadzorczego w ciągu 72 godzin od stwierdzenia naruszenia. Dla Swiss AG: FDPIC (Federal Data Protection and Information Commissioner). Dla Polish Sp. z o.o.: UODO (Urząd Ochrony Danych Osobowych). Wiodący organ ustalany zgodnie z art. 56 GDPR. - GDPR Art. 34: Jeśli naruszenie może powodować wysokie ryzyko dla praw i wolności osób — notyfikacja do osób, których dane dotyczą, bez zbędnej zwłoki. - NIS2: Early warning do właściwego CSIRT w ciągu 24 godzin, pełna notyfikacja w ciągu 72 godzin, raport końcowy w ciągu 1 miesiąca.

98.9 Evidence retention

Co jest zachowywane:

Typ dowodu	Źródło	Retencja	Format
Logi systemowe	Zone 4 (WORM)	5 lat (compliance), 3 lata (operational)	JSON + hash chain
Logi audytu admin	Management plane → Zone 4	5 lat	JSON z podpisem
Network flow data	G1/G2 firewalls	1 rok	NetFlow v9/IPFIX
Snapshoty konfiguracji	Config management	3 lata	YAML/JSON + hash
CDR processing logs	CDR pipeline → Zone 4	3 lata	JSON z hash
HSM audit logs	HSM modules	7 lat	Proprietary + export JSON
Komunikacja kryzysowa	Matrix crisis room	5 lat	Matrix event export
Decyzje dual auth	IAM audit trail	5 lat	JSON z podpisem
Memory dumps (jeśli captured)	Forensic capture	Do zamknięcia śledztwa + 1 rok	Raw + encrypted

Chain of custody: Każdy transfer dowodów musi być udokumentowany w formularzu łańcucha dowodowego zawierającym: identyfikator dowodu, hash SHA-256, datę i godzinę transferu, osobę przekazującą, osobę odbierającą, cel transferu, podpisy cyfrowe obu stron. Formularze przechowywane są w Zone 4.

Format przechowywania: Dowody muszą być przechowywane w formacie umożliwiającym weryfikację integralności. Zone 4 zapewnia niemodyfikowalność (WORM) i hash chain. Dodatkowa warstwa: BYO-KMS encryption dla klientów tier STATE. Dowody mogą być eksportowane na potrzeby organów ścigania wyłącznie po procedurze prawnej opisanej w playbooku 99.15.

Rozdział 99. Playbooks reagowania

Status: [N] Normatywny Odbiorca: SOC, IR Team, Administratorzy, Incident Commander Wpływ na baseline: Krytyczny Powiązane rozdziały: 98, 100, 101, 42, 55, 60

Każdy playbook definiuje kompletną procedurę reagowania na specyficzny typ incydentu. Playbooks muszą być wersjonowane, testowane w symulacjach (co kwartał) i aktualizowane po każdym incydencie (Rozdział 102.3).

99.1 Utrata terminala

Trigger: Operator zgłasza utratę terminala (kradzież, zagubienie, konfiskata). Alternatywnie: system wykrywa brak heartbeat terminala powyżej zdefiniowanego progu (konfigurowalny, domyślnie 24h).

Domyślna severity: P3 (Medium). Eskalacja do P2 jeśli terminal utracony w jurysdykcji wysokiego ryzyka lub operator jest osobą o podwyższonym profilu zagrożenia (dziennikarz, polityk opozycji). Eskalacja do P1 jeśli istnieją przesłanki, że utrata jest wynikiem celowej operacji (np. konfiskata przez służby w jurysdykcji autorytarnej).

Natychmiastowe działania (0–15 min): 1. Operator zgłasza utratę przez alternatywny kanał (telefon do SOC hotline, email szyfrowany, drugi terminal jeśli dostępny) 2. SOC unieważnia sesję terminala (session revoke immediate) 3. SOC blokuje token uwierzytelniający terminala w IAM 4. SOC unieważnia certyfikat terminala w PKI 5. Wpis do systemu incyidentowego z timestampem zgłoszenia

Kroki śledcze (15 min – 2 godz.): 1. Weryfikacja: czy terminal był aktywny po zgłoszonej utracie? (logi Zone 4 — ostatni heartbeat, ostatnia sesja) 2. Analiza logów sesji: czy po utracie wykonano jakiegokolwiek operację z tego terminala? 3. Ocena ryzyka: jakie workloady operator miał aktywne? (brak danych lokalnych — thin client) 4. Sprawdzenie: czy operator posiadał inne aktywne sesje z innych terminali? 5. Ustalenie okoliczności utraty (dokumentacja do raportu)

Containment: - Terminal nie przechowuje danych (thin client) — konfiskata terminala nie stanowi zagrożenia dla poufności danych - Blokada tokenu i certyfikatu eliminuje możliwość wykorzystania terminala do nawiązania sesji - Jeśli terminal posiadał skonfigurowany router — wykonanie playbooku 99.2 równolegle

Eradykacja: - Unieważnienie wszystkich credentials powiązanych z terminalem - Usunięcie terminala z rejestru urządzeń w IAM - Wygenerowanie nowych credentials dla nowego terminala

Recovery: 1. Provisioning nowego terminala dla operatora 2. Procedura sealed recovery key dla re-enrollment FIDO2 (dual authorization + 15-minutowe okno) 3. Weryfikacja nowego terminala (first-session test) 4. Przywrócenie operatora do pełnej operacyjności

Komunikacja: - Operator: potwierdzenie przyjęcia zgłoszenia, instrukcja re-enrollment - Klient (admin organizacji operatora): informacja o utracie terminala, potwierdzenie braku wycieku danych - Regulator: nie wymagana (brak naruszenia danych)

Dowody do zachowania: - Log unieważnienia sesji i credentials - Ostatni heartbeat terminala - Okoliczności utraty (zeznanie operatora) - Timeline działań containment

Lessons learned checklist: - [] Czy czas reakcji mieścił się w SLA? - [] Czy procedura re-enrollment przebiegła sprawnie? - [] Czy operator znał procedurę zgłaszania utraty? - [] Czy potrzebna aktualizacja szkolenia operatora?

99.2 Utrata routera

Trigger: Operator zgłasza utratę routera SYLION. System wykrywa brak heartbeat routera. Router nie odpowiada na zarządzanie zdalne.

Domyślna severity: P3 (Medium). Eskalacja do P2 jeśli router zawiera konfigurację VPN wskazującą na topologię sieci SYLION, lub jeśli utrata nastąpiła w okolicznościach wskazujących na celowe przejęcie.

Natychmiastowe działania (0–15 min): 1. SOC aktywuje kill switch routera (remote wipe konfiguracji, jeśli router jest online) 2. SOC unieważnia certyfikat IPsec routera w PKI 3. SOC blokuje IPsec SA powiązane z routerem na G1 4. SOC odcina wszystkie tunele VPN powiązane z routerem 5. Wpis do systemu incyidentowego

Kroki śledcze (15 min – 2 godz.): 1. Analiza logów: czy router był online po zgłoszonej utracie? 2. Weryfikacja: czy przez router przesyłano ruch po utracie? 3. Ocena: czy konfiguracja routera mogła ujawnić topologię sieci SYLION? 4. Sprawdzenie: czy kill switch zadziałał (potwierdzenie wipe)? 5. Analiza DNS query logs: czy router odpytywał podejrzane domeny?

Containment: - Kill switch czyści konfigurację routera (klucze IPsec, certyfikaty, konfigurację VPN) - Unieważnienie certyfikatu IPsec eliminuje możliwość nawiązania tunelu - Jeśli kill switch nie zadziałał (router offline) — konfiguracja jest zaszyfrowana kluczem sprzętowym; ryzyko odczytu oceniane jako niskie ale niezerowe

Eradykacja: - Usunięcie routera z rejestru urządzeń - Rotacja kluczy IPsec dla segmentu sieci, do którego router był przypisany - Weryfikacja, że żaden inny router w tej samej grupie nie wykazuje anomalii

Recovery: 1. Provisioning nowego routera z nową konfiguracją 2. Wygenerowanie nowych certyfikatów IPsec 3. Konfiguracja i test nowego routera (end-to-end connectivity test) 4. Dostarczenie i aktywacja nowego routera u operatora

Komunikacja: - Operator: instrukcja przejścia na alternatywne połączenie do czasu dostarczenia nowego routera - Klient (admin): informacja o wymianie routera - Regulator: nie wymagana (brak naruszenia danych)

Dowody do zachowania: - Logi kill switch (czy zadziałał, timestamp) - Ostatni heartbeat routera i logi komunikacji - Logi IPsec SA revocation - Okoliczności utraty

Lessons learned checklist: - [] Czy kill switch zadziałał poprawnie? - [] Czy czas dostarczenia replacement routera jest akceptowalny? - [] Czy konfiguracja routera była odpowiednio zabezpieczona? - [] Czy operator wiedział, jak postępować bez routera?

99.3 Kompromitacja G1

Trigger: G1 (gateway warstwy pierwszej) wykazuje oznaki kompromitacji: nieoczekiwany ruch sieciowy, zmiany konfiguracji bez autoryzacji, niepowodzenie sprawdzenia integralności (integrity check failure), anomalie w logach ACL, nieautoryzowane SA establishments.

Domyślna severity: P1 (Critical). G1 jest krytycznym komponentem infrastruktury — jego kompromitacja może umożliwić przechwycenie lub manipulację ruchu operatorów.

Natychmiastowe działania (0–15 min): 1. Incident Commander mobilizuje IR Team (pager/call, 24/7) 2. Aktywacja kryzysowego pokoju Matrix 3. Natychmiastowe odcięcie skompromitowanego G1 od sieci (ACL update na upstream switch/router) 4. Przekierowanie ruchu na backup G1 (jeśli dostępny w konfiguracji HA) 5. Zamrożenie wszystkich sesji przechodzących przez skompromitowany G1 6. Zabezpieczenie logów Zone 4 z okresu anomalii (snapshot) 7. Powiadomienie CISO, CTO, CEO

Kroki śledcze (15 min – 2 godz.): 1. Analiza logów Zone 4: kiedy pojawiły się pierwsze anomalie? 2. Sprawdzenie integralności firmware/konfiguracji G1 (hash comparison z golden image) 3. Analiza ACL: czy były nieautoryzowane zmiany? 4. Analiza ruchu sieciowego: czy G1 komunikował się z nieoczekiwanymi

endpointami? 5. Weryfikacja certyfikatów G1 (czy nie podmienione) 6. Analiza IPsec SA: czy ustanowiono nieautoryzowane tunele? 7. Sprawdzenie: czy inne G1 w klastrze wykazują podobne anomalie (lateral movement)? 8. Analiza timeline: korelacja z innymi alertami SIEM

Containment: - Izolacja sieciowa skompromitowanego G1 - Przekierowanie ruchu na alternatywną ścieżkę - Rewokacja certyfikatów G1 - Aktualizacja ACL na wszystkich G1 — blokada komunikacji ze skompromitowaną instancją - Wstrzymanie provisioning nowych SA przez skompromitowany G1

Eradykacja: 1. Deprovisioning skompromitowanej instancji G1 (full destroy) 2. Audyt konfiguracji wszystkich G1 w klastrze (sprawdzenie lateral spread) 3. Rotacja certyfikatów wszystkich G1 w dotkniętym segmencie 4. Deploy nowej instancji G1 z verified golden image 5. Rotacja kluczy IPsec dla dotkniętych tuneli 6.

Weryfikacja integralności: porównanie konfiguracji z expected state

Recovery: 1. Nowa instancja G1 przechodzi pełny test suite (connectivity, ACL, IPsec SA, integrity) 2. Stopniowe przywracanie ruchu (10% → 50% → 100%) 3. Wzmocniony monitoring nowego G1 przez 7 dni 4. Weryfikacja end-to-end session establishment przez nowy G1

Komunikacja: - Wewnętrzna: crisis room updates co 30 minut, escalation chain aktywna - Klient: notyfikacja o degradacji usługi, ETA przywrócenia, potwierdzenie brak wycieku danych (jeśli potwierdzone) - Regulator: ocena czy naruszenie wymaga notyfikacji GDPR/NIS2; jeśli tak — 24h early warning (NIS2) - Publiczna: tylko jeśli incydent jest publicznie widoczny lub wymaga tego regulacja

Dowody do zachowania: - Pełne logi Zone 4 z okresu incydu (hash-chained, immutable) - Snapshot konfiguracji skompromitowanego G1 - Network captures (jeśli dostępne) - ACL change logs - IPsec SA establishment/teardown logs - Timeline korelacji z SIEM

Lessons learned checklist: - [] Jak szybko wykryto anomalie? - [] Czy backup G1 przejął ruch bez przerwy? - [] Jaki był wektor ataku? - [] Czy golden image registry jest bezpieczny? - [] Czy potrzebne są dodatkowe kontrole integrity check?

99.4 Kompromitacja G2

Trigger: G2 (policy engine warstwy drugiej) wykazuje nieoczekiwane zachowanie: nieautoryzowane zmiany polityk, policy evaluation zwraca wyniki niezgodne z oczekiwanymi, nieautoryzowany dostęp do management API, anomalie w policy decision logs.

Domyślna severity: P1 (Critical). G2 jako policy engine kontroluje autoryzację operacji — jego kompromitacja może umożliwić eskalację uprawnień lub obejście polityk Zero Trust.

Natychmiastowe działania (0–15 min): 1. Incident Commander mobilizuje IR Team 2. Aktywacja kryzysowego pokoju Matrix 3. Natychmiastowy policy freeze — zablokowanie wszelkich zmian polityk na wszystkich G2 4. Przełączenie na backup G2 (jeśli konfiguracja HA aktywna) 5. Zabezpieczenie policy decision logs z Zone 4 6. Audit trail management API — zabezpieczenie logów operacji administracyjnych 7. Powiadomienie CISO, CTO

Kroki śledcze (15 min – 2 godz.): 1. Diff polityk: porównanie aktualnych polityk z last known good state 2. Analiza: kto miał dostęp do management API G2? Weryfikacja dual auth records 3. Analiza policy decisions: czy podejmowano decyzje niezgodne z politykami? 4. Sprawdzenie: czy nastąpiła eskalacja uprawnień jakiegokolwiek operatora/admina? 5. Korelacja z innymi alertami: czy kompromitacja G2 jest częścią szerszego ataku? 6. Weryfikacja integralności binariów G2 (hash comparison)

Containment: - Policy freeze na wszystkich G2 - Izolacja skompromitowanego G2 z sieci management - Przywrócenie polityk do last known good snapshot - Natychmiastowa rewokacja tokenów API management

Eradykacja: 1. Deprovisioning skompromitowanej instancji G2 2. Audyt polityk na wszystkich G2 — weryfikacja spójności 3. Rotacja credentials management API 4. Deploy nowej instancji G2 z verified image 5. Przywrócenie polityk z audit-trailed backup 6. Weryfikacja policy evaluation (test suite)

Recovery: 1. Nowy G2 przechodzi pełny test suite (policy evaluation, API access control, integration tests) 2. Weryfikacja end-to-end: czy decyzje polityk są poprawne? 3. Stopniowe przywracanie — canary testing z ograniczoną liczbą operatorów 4. Wzmocniony monitoring 7 dni

Komunikacja: - Wewnętrzna: crisis room co 30 minut - Klient: jeśli zmieniono polityki — notyfikacja o potencjalnym wpływie na autoryzację operatorów - Regulator: ocena konieczności notyfikacji GDPR/NIS2

Dowody do zachowania: - Policy decision logs z Zone 4 - Diff polityk (skompromitowane vs known-good) - Management API access logs - Dual auth records z okresu incydu - Hash integrity check results

Lessons learned checklist: - [] Jak przeszły nieautoryzowane zmiany polityk? (gap w dual auth?) - [] Czy monitoring policy drift działał poprawnie? - [] Czy policy freeze zadziałał w wymaganym czasie? - [] Jakie dodatkowe kontrole są potrzebne?

99.5 Kompromitacja session broker

Trigger: Session broker wykazuje anomalie: dostarcza nieoczekiwaną zawartość sesji, session integrity check failure, nieautoryzowane przekierowania sesji, anomalie w session establishment logs.

Domyślna severity: P1 (Critical). Session broker zarządza powiązaniem operatorów z workloadami — jego kompromitacja może umożliwić man-in-the-middle lub przekierowanie sesji do złośliwych workloadów.

Natychmiastowe działania (0–15 min): 1. Mobilizacja IR Team + aktywacja crisis room 2. Natychmiastowe unieważnienie wszystkich aktywnych sesji (full session revoke) 3. Przełączenie na backup session broker 4. Izolacja skompromitowanego brokera z sieci 5. Zabezpieczenie session logs z Zone 4 6. Powiadomienie CISO, CTO

Kroki śledcze (15 min – 2 godz.): 1. Analiza session routing: czy sesje były przekierowywane do nieoczekiwanych workloadów? 2. Weryfikacja integralności session brokera (binary hash, config diff) 3. Analiza: jakie sesje były aktywne w momencie kompromitacji? 4. Sprawdzenie: czy operatorzy łączyli się z poprawnymi workloadami? 5. Korelacja z innymi alertami (G1/G2 anomalies, workload anomalies) 6. Analiza session tokens: czy wygenerowano nieautoryzowane tokeny?

Containment: - Full session revoke — wszystkie aktywne sesje zakończone - Izolacja sieciowa skompromitowanego brokera - Rotacja kluczy sesyjnych (session key rotation) - Blokada session establishment do czasu przywrócenia zaufanego brokera

Eradykacja: 1. Deprovisioning skompromitowanego brokera 2. Audyt konfiguracji backup brokera 3. Rotacja wszystkich session secrets i signing keys 4. Deploy nowego brokera z verified image 5. Weryfikacja session routing tables

Recovery: 1. Test nowego brokera: session establishment, routing verification, integrity check 2. Stopniowe przywracanie sesji (canary → pilot → full) 3. Operatorzy muszą re-establish sesje (brak automatic reconnection z tokenami sprzed incydentu) 4. Wzmocniony monitoring 7 dni

Komunikacja: - Klient: natychmiastowa notyfikacja o przerwaniu sesji, instrukcja reconnect - Jeśli sesje były przekierowane do złośliwych workloadów: P1 eskalacja, ocena wycieku danych

Dowody do zachowania: - Session routing logs z Zone 4 - Session establishment/teardown logs - Binary hash comparison (broker) - Network captures (session traffic) - Lista dotkniętych operatorów i sesji

Lessons learned checklist: - [] Jak szybko wykryto anomalię w session routing? - [] Czy backup broker przejął bez problemów? - [] Czy operatorzy doświadczyli przerwy? Jak długiej? - [] Jakie mechanizmy wykrywania session integrity failures?

99.6 Kompromitacja workloadu

Trigger: Workload (microVM operatora) wykazuje oznaki kompromitacji: nieoczekiwany egress traffic, anomalne zachowanie procesów, próba eskalacji uprawnień, naruszenie polityk sandboxu Firecracker, komunikacja z C2.

Domyślna severity: P2 (High). Eskalacja do P1 jeśli istnieją oznaki lateral movement do innych workloadów lub kompromitacja infrastruktury zarządzającej.

Natychmiastowe działania (0–15 min): 1. SOC potwierdza anomalię (korelacja alertów) 2. Natychmiastowe zniszczenie skompromitowanej microVM (Firecracker destroy) 3. Izolacja sieciowa operatora (network policy: block all egress) 4. Zabezpieczenie memory snapshot (jeśli AMD SEV-SNP/TDX pozwala na forensic capture) 5. Powiadomienie IR Team

Kroki śledcze (15 min – 2 godz.): 1. Analiza logów Zone 4: timeline anomalii workloadu 2. Analiza network flow: jaki egress traffic generował workload? Do jakich endpointów? 3. Sprawdzenie: czy workload próbował komunikować się z innymi microVM? (lateral movement) 4. Analiza CDR logs: czy workload staging zone wykazuje anomalie? 5. Weryfikacja: czy obraz microVM, z którego uruchomiono workload, jest integrity-valid? 6. Analiza: jaki operator korzystał z workloadu? Czy jego konto jest kompromitowane? 7. Sprawdzenie Firecracker isolation: czy sandbox microVM zadziałał poprawnie?

Containment: - Destroyed microVM nie istnieje — brak danych do odzyskania przez atakującego - Izolacja sieciowa zapobiega lateral movement - Weryfikacja sąsiednich workloadów (microVM na tym samym hoście fizycznym) - Jeśli podejrzenie kompromitacji konta operatora — execution playbook 99.1 (utrata sesji)

Eradykacja: 1. Weryfikacja integralności obrazu microVM (golden image hash) 2. Jeśli obraz zatruty — eskalacja do supply chain compromise (99.14) 3. Odtworzenie czystej microVM z verified image 4. Ponowne provisioning środowiska operatora 5. Rotacja credentials operatora (jeśli podejrzenie kompromitacji konta)

Recovery: 1. Nowa microVM przechodzi verification test 2. Operator re-establish sesję 3. Wzmocniony monitoring workloadu przez 72 godziny 4. Potwierdzenie z operatorem, że środowisko działa poprawnie

Komunikacja: - Operator: informacja o konieczności ponownego nawiązania sesji - Klient (admin): informacja o incydencie z workloadem, potwierdzenie containment - Regulator: ocena konieczności notyfikacji

Dowody do zachowania: - Memory snapshot (jeśli captured) - Network flow data - CDR processing logs - Logi Firecracker isolation - Zone 4 logs z okresu anomalii

Lessons learned checklist: - [] Jak workload został skompromitowany? (wektor ataku) - [] Czy izolacja Firecracker zadziałała (brak lateral movement)? - [] Czy monitoring anomalii wykrył incydent wystarczająco szybko? - [] Czy obraz microVM wymaga hardening?

99.7 Kompromitacja Matrix

Trigger: Matrix homeserver wykazuje oznaki kompromitacji: naruszenie integralności wiadomości, nieautoryzowana federacja z zewnętrznym serwerem, anomalie w event signing, nieautoryzowany dostęp do room state, podejrzone device verification failures.

Domyślna severity: P1 (Critical). Matrix homeserver jest centrum komunikacji — kompromitacja zagraża poufności i integralności komunikacji operatorów.

Natychmiastowe działania (0–15 min): 1. Mobilizacja IR Team + aktywacja crisis room (alternatywny kanał — nie Matrix!) 2. Natychmiastowe zablokowanie federacji z nieautoryzowanymi serwerami 3. Zamrożenie event processing na skompromitowanym homeserverze 4. Przełączenie na backup homeserver (jeśli konfiguracja HA) 5. Zabezpieczenie event logs i room state z Zone 4 6. Powiadomienie CISO

Kroki śledcze (15 min – 2 godz.): 1. Analiza federation logs: czy homeserver federował z nieautoryzowanymi serwerami? 2. Weryfikacja event signatures: czy wiadomości mają prawidłowe podpisy? 3. Analiza room state: czy nastąpiły nieautoryzowane zmiany w membership, power levels? 4. Sprawdzenie device verification: czy pojawiły się nieznane urządzenia? 5. Analiza: czy E2EE keys były narażone? (room keys, device keys) 6. Korelacja z innymi alertami w infrastrukturze SYLION

Containment: - Zablokowanie federacji (isolated homeserver) - Zamrożenie event processing - Unieważnienie device keys skompromitowanych urządzeń - Jeśli E2EE keys narażone — wymuszenie key rotation w dotkniętych room'ach

Eradykacja: 1. Deprovisioning skompromitowanego homeservera 2. Deploy nowej instancji z verified image 3. Odtworzenie room state z zaufanego backupu (pre-compromise state) 4. Rotacja signing keys homeservera 5. Wymuszenie device re-verification dla wszystkich operatorów 6. Audyt federation allowlist

Recovery: 1. Nowy homeserver przechodzi test suite (event routing, federation, E2EE) 2. Operatorzy muszą ponownie zweryfikować urządzenia 3. Stopniowe przywracanie room'ów 4. Wzmocniony monitoring 7 dni

Komunikacja: - Klient: informacja o przerwie w komunikacji Matrix, ETA przywrócenia - Uwaga: crisis room musi działać na alternatywnym kanale (nie na potencjalnie skompromitowanym Matrix)

Dowody do zachowania: - Event logs z Zone 4 (hash-chained) - Federation logs - Device verification logs - Room state snapshots - Signing key records

Lessons learned checklist: - [] Jak zadziałał alternatywny kanał crisis communication? - [] Czy federacja była poprawnie ograniczona (allowlist)? - [] Czy E2EE zapewniło ochronę treści mimo kompromitacji homeservera? - [] Jakie dodatkowe monitoring rules dla Matrix?

99.8 Nadużycie workloadu Signal

Trigger: Workload Signal wykazuje próby nadużycia: próba exfiltracji danych przez kanał Signal, próba obejścia polityk CDR, nieautoryzowane wysyłanie załączników, anomalia w routing wiadomości Signal.

Domyślna severity: P2 (High). Eskalacja do P1 jeśli potwierdzona exfiltracja danych.

Natychmiastowe działania (0–15 min): 1. SOC weryfikuje anomalię 2. Natychmiastowa izolacja workloadu Signal operatora (network block na egress) 3. Zamrożenie sesji operatora 4. Zabezpieczenie logów CDR i policy decision logs 5. Powiadomienie IR Team

Kroki śledcze (15 min – 2 godz.): 1. Analiza CDR logs: czy operator próbował wysłać pliki z obejściem CDR? 2. Analiza policy decisions G2: jakie polityki były aktywne dla tego workloadu? 3. Weryfikacja: czy nastąpiła próba policy bypass (np. manipulacja nagłówków)? 4. Analiza volume: jaka ilość danych przesłano przez Signal workload? 5. Korelacja z zachowaniem operatora: czy jest to insider threat? 6. Sprawdzenie: czy inne workloady Signal wykazują podobne wzorce?

Containment: - Izolacja workloadu Signal - Zamrożenie sesji operatora - Wzmocnione polityki CDR dla segmentu operatora - Jeśli potwierdzona exfiltracja — eskalacja do P1, playbook 99.9

Eradykacja: 1. Zniszczenie skompromitowanego/nadużywanego workloadu Signal 2. Odtworzenie z czystego obrazu z zastrzonym policy profilem 3. Jeśli insider threat: procedura revokacji dostępu operatora (z HR/Legal) 4. Weryfikacja polityk CDR — uszczelnienie jeśli wykryto lukę

Recovery: 1. Nowy workload Signal z enhanced monitoring 2. Operator (jeśli nie insider threat): re-provisioning z nauką o politykach 3. Wzmocniony monitoring 30 dni

Komunikacja: - Klient (admin): informacja o anomalii, request o weryfikację zasadności działań operatora - Jeśli potwierdzona exfiltracja: komunikacja zgodna z playbook 99.9

Dowody do zachowania: - CDR processing logs - Policy decision logs G2 - Signal workload network flow data - Operator activity timeline - Volume i destination analiza

Lessons learned checklist: - [] Czy polityki CDR były wystarczające? - [] Czy monitoring anomalii Signal workload jest adekwatny? - [] Czy potrzebne dodatkowe kontrole dla kanału Signal? - [] Jakie procedury dla insider threat?

99.9 Exfiltration attempt

Trigger: System wykrywa próbę masowej exfiltracji danych: duże wolumeny transferów przez CDR, anomalia w staging zone, bulk export, nietypowe zapytania API, masowe kopiowanie do kanałów wyjściowych.

Domyślna severity: P1 (Critical). Każda potwierdzona próba exfiltracji jest P1.

Natychmiastowe działania (0–15 min): 1. Mobilizacja IR Team + crisis room 2. Natychmiastowe wstrzymanie wszystkich transferów CDR z dotkniętego konta/operatora 3. Izolacja workloadu operatora (network block) 4. Zamrożenie sesji operatora 5. Zabezpieczenie staging zone snapshot 6. Wstrzymanie bulk export na całej platformie (temporary freeze) 7. Powiadomienie CISO, CTO, CEO, Legal

Kroki śledcze (15 min – 2 godz.): 1. Analiza CDR logs: jakie pliki były w staging, jakie typy danych, jakie wolumeny? 2. Analiza destination: dokąd kierowano exfiltrację? (external endpoints, email, Signal) 3. Analiza konta operatora: czy konto zostało przejęte? (login anomalies, geolocation mismatch) 4. Analiza timeline: kiedy zaczęło się anomalne zachowanie? 5. Sprawdzenie: czy inne konta wykazują podobne wzorce (coordinated exfiltration)? 6. Korelacja z innymi alertami: supply chain, session broker, workload anomalies? 7. Analiza zawartości staging zone: jakie dane były celem (classification level)?

Containment: - Pełna izolacja operatora (sesja, workload, CDR) - Temporary CDR freeze na platformie (jeśli podejrzenie coordinated attack) - Wzmocnione polityki egress na G1/G2 - Jeśli insider threat: natychmiastowe powiadomienie Legal i HR

Eradykacja: 1. Zniszczenie skompromitowanego workloadu 2. Rewokacja dostępu operatora 3. Uszczelnienie polityk CDR (jeśli bypass wykryty) 4. Rotacja credentials operatora 5. Audit trail dla wszystkich operatorów w organizacji klienta

Recovery: 1. Przywrócenie usług CDR po weryfikacji polityk 2. Wzmocniony monitoring egress traffic 30 dni 3. Enhanced DLP policies dla dotkniętej organizacji

Komunikacja: - Klient (management): natychmiastowa notyfikacja o próbie exfiltracji z oceną zakresu - Legal: ocena obowiązków notyfikacyjnych (GDPR, contractual) - Regulator: jeśli dane osobowe — GDPR Art. 33 (72h), NIS2 early warning (24h) - Publiczna: konsultacja z Legal, decyzja o zakresie disclosure

Dowody do zachowania: - CDR staging zone snapshot (pełna kopia) - CDR processing logs - Network flow data (egress) - Operator activity timeline - Policy decision logs G2 - Login/session logs operatora - Analiza zawartości exfiltrowanych danych

Lessons learned checklist: - [] Jak szybko wykryto anomalię? - [] Czy polityki CDR zapobiegły/ograniczyły exfiltrację? - [] Czy potrzebne są dodatkowe DLP controls? - [] Jakie dane były zagrożone? Jaki impact? - [] Czy monitoring bulk transfers jest wystarczający?

99.10 Suspicious admin activity

Trigger: Administrator wykonuje nieoczekiwane operacje uprzywilejowane: próba obejścia dual authorization, masowe zmiany polityk, dostęp do danych operatorów bez uzasadnienia, nieautoryzowane użycie API management, operacje poza normalnymi godzinami pracy, geolocation mismatch.

Domyślna severity: P2 (High). Eskalacja do P1 jeśli potwierdzone obejście dual auth lub aktywny dostęp do danych operatorów.

Natychmiastowe działania (0–15 min): 1. SOC weryfikuje anomalię (korelacja z normalnym wzorcem aktywności admina) 2. Natychmiastowe zawieszenie sesji administracyjnej (session suspend, nie terminate — zachowanie dowodów) 3. Tymczasowe zablokowanie konta admina w IAM 4. Zabezpieczenie audit trail admina z Zone 4 5. Powiadomienie CISO bezpośrednio (pominięcie potencjalnie skompromitowanego admina w łańcuchu eskalacji)

Kroki śledcze (15 min – 2 godz.): 1. Analiza audit trail: jakie operacje wykonał admin? Timeline? 2. Sprawdzenie dual auth records: czy operacje wymagały dual auth? Czy ją uzyskały? 3. Analiza: czy admin miał uzasadnienie biznesowe dla tych operacji? 4. Weryfikacja geolocation i IP: czy logował się z normalnej lokalizacji? 5. Sprawdzenie: czy konto admina mogło zostać przejęte (compromised credentials)? 6. Analiza: czy admin próbował wyczyścić audit trail? (niemożliwe w Zone 4, ale próba jest dodatkowym indicator) 7. Korelacja z HR: czy admin jest w trakcie wypowiedzenia/konfliktu?

Containment: - Zawieszenie konta admina - Wymuszenie dual auth na wszystkich operacjach administracyjnych (temporarily heightened) - Rewizja ostatnich zmian dokonanych przez admina (rollback jeśli nieautoryzowane) - Powiadomienie drugiego admina upoważnionego do dual auth

Eradykacja: 1. Jeśli konto przejęte: pełna rotacja credentials admina, FIDO2 re-enrollment 2. Jeśli insider threat: rewokacja dostępu, współpraca z Legal/HR 3. Rollback nieautoryzowanych zmian 4. Weryfikacja integralności systemu po operacjach admina

Recovery: 1. Jeśli konto przejęte i admin zweryfikowany: przywrócenie dostępu po re-enrollment 2. Wzmocniony monitoring konta admina 90 dni 3. Jeśli insider threat: provisioning replacement admin

Komunikacja: - CISO: bezpośrednia notyfikacja (pominięcie admina w łańcuchu) - Legal: jeśli insider threat — współpraca ws. postępowania - Klient: jeśli działania admina wpłynęły na operatorów klienta

Dowody do zachowania: - Kompletny audit trail admina z Zone 4 - Dual auth records - Session logs (w tym suspended session) - Geolocation/IP data - Timeline korelacja z innymi zdarzeniami

Lessons learned checklist: - [] Czy dual auth zadziałał jako kontrola? - [] Czy monitoring privileged activity jest wystarczający? - [] Czy procedury vetting admina są adekwatne? - [] Jakie dodatkowe behavioral analytics potrzebne?

99.11 Degradacja SIEM

Trigger: Pipeline logów wykazuje awarie: logi nie docierają do Zone 4, opóźnienie pipeline przekracza próg (>5 minut), hash chain integrity failure w Zone 4, alerting engine nie generuje powiadomień, dashboard monitoringu nieaktualny.

Domyślna severity: P2 (High). SIEM jest kluczowy dla detekcji — jego degradacja oznacza blind spot w monitoringu. Eskalacja do P1 jeśli degradacja SIEM zbiegła się z innymi anomaliami (wskazanie na celowe oślepienie monitoringu).

Natychmiastowe działania (0–15 min): 1. SOC potwierdza degradację (manual check pipeline, Zone 4 ingestion rate) 2. Aktywacja alternatywnego mechanizmu monitoringu (manual log review, backup pipeline jeśli dostępny) 3. Podniesienie poziomu czujności — manual monitoring przez dodatkowych analityków 4. Sprawdzenie: czy degradacja SIEM jest izolowana, czy towarzyszy jej inna anomalia? 5. Powiadomienie IR Team o potencjalnym blind spot

Kroki śledcze (15 min – 2 godz.): 1. Diagnoza root cause degradacji: awaria pipeline (software), awaria storage Zone 4 (hardware), awaria sieci (transport) 2. Sprawdzenie integrity hash chain w Zone 4: czy istnieją luki (gaps) w logach? 3. Analiza: czy ktoś celowo degradował SIEM (sabotaż)? 4. Weryfikacja: jakie komponenty nie raportują logów? 5. Ocena: jak długo trwa blind spot? Jakie zdarzenia mogły nie zostać wykryte?

Containment: - Alternatywny monitoring (manual log review, backup pipeline) - Wzmocniony perimeter monitoring na G1/G2 (zwiększone logowanie lokalne) - Jeśli podejrzenie sabotażu — eskalacja jako incydent bezpieczeństwa P1

Eradykacja: 1. Naprawa pipeline (restart serwisów, naprawa transportu, odtworzenie storage) 2. Jeśli sabotaż: procedura eradykacji per wektor ataku 3. Weryfikacja integralności hash chain po przywróceniu 4. Back-fill logów z lokalnych buforów komponentów (jeśli dostępne)

Recovery: 1. Potwierdzenie pełnego przepływu logów (end-to-end test) 2. Weryfikacja hash chain continuity 3. Analiza retrospektywna: przegląd logów z okresu blind spot 4. Przywrócenie normalnych thresholds alertów

Komunikacja: - Wewnętrzna: powiadomienie wszystkich zespołów o degradacji monitoringu - Klient: nie wymagana (chyba że degradacja SIEM skutkowała przeoczeniem incydentu klienta)

Dowody do zachowania: - Logi diagnostyczne pipeline - Hash chain verification results - Timeline degradacji - Lista komponentów, które nie raportowały

Lessons learned checklist: - [] Jak szybko wykryto degradację SIEM? - [] Czy alternatywny monitoring był skuteczny? - [] Czy istnieją luki w logach? Jak je uzupełnić? - [] Czy pipeline wymaga redundancji?

99.12 Backup failure

Trigger: Zadanie backupowe zakończyło się błędem. Test przywracania (restore test) zakończył się niepowodzeniem. Integrity check backupu wykrył niezgodność. Storage backupowy wykazuje anomalie (capacity, latency, errors).

Domyślna severity: P3 (Medium). Eskalacja do P2 jeśli backup failure dotyczy danych krytycznych (Zone 4, HSM keys, Matrix state) lub jeśli jest to powtarzający się problem.

Natychmiastowe działania (0–15 min): 1. SOC identyfikuje dotkniętą usługę/komponent 2. Sprawdzenie: czy ostatni poprawny backup istnieje? Jak stary jest? 3. Ocena RPO (Recovery Point Objective): czy utrata tego backupu narusza RPO? 4. Weryfikacja: czy inne zadania backupowe działają poprawnie? 5. Powiadomienie Ops Team

Kroki śledcze (15 min – 2 godz.): 1. Diagnoza: przyczyna failure (storage full, network error, software bug, permission issue) 2. Weryfikacja integralności istniejących backupów (hash check) 3. Sprawdzenie: czy backup storage jest dostępny i zdrowy? 4. Analiza trendu: czy jest to jednorazowa awaria czy powtarzający się wzorec? 5. Weryfikacja: czy backup encryption keys są dostępne (BYO-KMS jeśli STATE tier)

Containment: - Immediate: retry zadania backupowego - Jeśli storage problem: przełączenie na alternatywny storage - Eskalacja jeśli brak poprawnego backupu w oknie RPO

Eradykacja: 1. Naprawa przyczyny awarii 2. Weryfikacja konfiguracji backupu 3. Test restore z ostatniego poprawnego backupu 4. Jeśli data corruption: identyfikacja źródła i naprawa

Recovery: 1. Poprawne wykonanie backupu 2. Potwierdzenie restore test 3. Przywrócenie normalnego harmonogramu backupów 4. Weryfikacja alertingu na backup failures

Komunikacja: - Wewnętrzna: Ops Team, SOC Manager - Klient: jeśli naruszono RPO — notyfikacja z oceną ryzyka

Dowody do zachowania: - Backup job logs - Storage health reports - Restore test results - Timeline failure

Lessons learned checklist: - [] Czy monitoring backup failures działa? - [] Czy RPO jest realistyczne? - [] Czy restore testy są wykonywane regularnie? - [] Czy storage backupowy wymaga upgrade?

99.13 Region outage

Trigger: Primaryregion jest niedostępny: utrata łączności z regionem, awaria compute/storage w regionie, disaster (natural, power, network) wpływający na region.

Domyślna severity: P1 (Critical). Outage regionu wpływa na wszystkich operatorów w regionie.

Natychmiastowe działania (0–15 min): 1. Monitoring potwierdza outage (nie fałszywy alarm — weryfikacja z wielu punktów) 2. Incident Commander aktywuje DR plan 3. Aktywacja failover do regionu zapasowego (jeśli skonfigurowany) 4. Komunikacja do operatorów: informacja o degradacji, ETA przywrócenia 5.

Powiadomienie CISO, CTO, CEO 6. Aktywacja crisis room

Kroki śledcze (15 min – 2 godz.): 1. Diagnoza: przyczyna outage (infrastruktura dostawcy, sieć, zasilanie, atak?) 2. Ocena: jaki jest oczekiwany czas przywrócenia regionu primary? 3. Weryfikacja: czy failover do backup regionu działa poprawnie? 4. Sprawdzenie: czy dane w regionie primary są bezpieczne (replication status)? 5. Ocena: czy outage jest wynikiem ataku (DDoS, sabotaż)?

Containment: - Failover do backup regionu - DNS/routing update kierujący ruch do backup regionu - Jeśli atak: procedury anty-DDoS, współpraca z ISP

Eradykacja: 1. Po przywróceniu regionu primary: weryfikacja integralności infrastruktury 2. Data reconciliation między regionami (replication catch-up) 3. Jeśli atak: eradykacja zgodnie z wektorem ataku

Recovery: 1. Weryfikacja regionu primary (health checks, integrity tests) 2. Stopniowe przywracanie ruchu do primary (10% → 50% → 100%) 3. Weryfikacja data consistency po failback 4. Dezaktywacja trybu DR

Komunikacja: - Klient: statusy co 30 minut (P1), informacja o failover, ETA full recovery - Regulator: NIS2 reporting jeśli kwalifikuje się jako significant incident - Publiczna: jeśli outage jest publicznie widoczny (status page update)

Dowody do zachowania: - Timeline outage - Failover logs - Data replication status logs - Root cause analysis

Lessons learned checklist: - [] Jak szybko failover zadziałał? - [] Czy RPO/RTO zostały dotrzymane? - [] Czy operatorzy doświadczyli przerwy? Jak długiej? - [] Czy DR plan wymaga aktualizacji?

99.14 Supply chain compromise

Trigger: Zidentyfikowano podatność w zależności (dependency vulnerability), wykryto kompromitację build pipeline, tamper detection na artefaktach (images, binaries, libraries), CVE w krytycznym komponencie, SBOM alert.

Domyślna severity: P1 (Critical) jeśli aktywnie eksploatowany lub dotyczy krytycznych komponentów (Firecracker, Matrix, G1/G2). P2 (High) jeśli podatność zidentyfikowana ale nie potwierdzona eksploatacja.

Natychmiastowe działania (0–15 min): 1. IR Team identyfikuje zakres — jakie komponenty korzystają z dotkniętej zależności? 2. Jeśli aktywna eksploatacja: natychmiastowa izolacja dotkniętych komponentów 3. Wstrzymanie deploy pipeline (no new deployments until verified) 4. Zabezpieczenie SBOM i build logs 5. Powiadomienie CISO, CTO

Kroki śledcze (15 min – 2 godz.): 1. Analiza SBOM: które dokładnie komponenty zawierają dotkniętą zależność? 2. Weryfikacja build pipeline: czy pipeline jest skompromitowany? (code signing verification) 3. Sprawdzenie artefaktów: hash comparison z known-good (SLSA provenance) 4. Analiza: czy dotkniętych komponentów użyto w produkcji? Jak dawno? 5. Ocena eksploatowalności: czy podatność jest exploitable w kontekście SYLION? 6. Korelacja: czy istnieją oznaki, że podatność została już wykorzystana?

Containment: - Wstrzymanie deploy pipeline - Izolacja komponentów z aktywnie exploitowaną podatnością - Przywrócenie artefaktów do last known-good version (przed compromise) - Jeśli build pipeline skompromitowany: przełączenie na backup build environment

Eradykacja: 1. Usunięcie dotkniętej zależności lub aktualizacja do patched version 2. Rebuilding artefaktów z czystych źródeł 3. Re-signing artefaktów (new code signing keys jeśli pipeline compromised) 4. Audyt pełnego SBOM — weryfikacja wszystkich zależności 5. Wdrożenie dodatkowych kontroli (pinned dependencies, SLSA v1.2 Level 3+)

Recovery: 1. Deploy zaktualizowanych artefaktów (canary → full rollout) 2. Weryfikacja integrity na wszystkich komponentach produkcyjnych 3. Wzmocniony monitoring 30 dni

Komunikacja: - Klient: jeśli podatność mogła wpłynąć na dane — notyfikacja - Industry: disclosure do CVE/CERT jeśli dotyczy open-source component - Regulator: jeśli spełnia kryteria NIS2

Dowody do zachowania: - SBOM snapshots (before/after) - Build pipeline logs - Artefact hashes (compromised vs clean) - CVE details i analiza exploitability - SLSA provenance records

Lessons learned checklist: - [] Jak szybko wykryto supply chain compromise? - [] Czy SBOM monitoring jest wystarczający? - [] Czy SLSA controls zapobiegły/ograniczyły impact? - [] Jakie dodatkowe dependency controls potrzebne?

99.15 Legal seizure request

Trigger: Żądanie organów ścigania lub instytucji rządowej dotyczące wydania danych, dostępu do systemu, lub konfiskaty sprzętu. Żądanie może dotyczyć dowolnej jurysdykcji (Szwajcaria, USA, Polska, inna).

Domyślna severity: P2 (High). Eskalacja do P1 jeśli żądanie obejmuje natychmiastowy dostęp do danych klientów lub grozi przerwaniem usługi.

Natychmiastowe działania (0–15 min): 1. Osoba przyjmująca żądanie NIE podejmuje żadnych działań technicznych 2. Natychmiastowe przekazanie żądania do działu Legal (General Counsel) 3. Legal dokonuje wstępnej oceny: czy żądanie jest formalne i zgodne z prawem? 4. Jeśli żądanie wymaga natychmiastowej odpowiedzi (przeszukanie z nakazem): Legal jest obecny fizycznie 5. Powiadomienie CISO i CEO 6. NIE informuje się klienta, którego dane dotyczą — dopóki Legal nie oceni, czy notyfikacja jest dozwolona prawnie (gag order?)

Kroki śledcze (15 min – 2 godz.): 1. Legal analizuje żądanie: jurysdykcja, podstawa prawna, zakres, proporcjonalność 2. Ocena jurysdykcyjna: - Szwajcaria (Swiss AG — primary entity): DSGPA, MLA procedures, FDPIC notification requirements - USA (US LLC): CLOUD Act, subpoena, warrant, national security letter - Polska (Sp. z o.o.): KPK, ustawa o Policji, ABW 3. Sprawdzenie: czy żądanie jest proporcjonalne? Czy SYLION może zakwestionować zakres? 4. Ocena: co SYLION może technicznie dostarczyć (zone 4 logs, metadata) vs czego nie może (E2EE content, terminal data, ephemeral session keys) 5. Konsultacja z zewnętrznym counsel jeśli cross-border

Containment: - Prawny: zabezpieczenie (litigation hold) danych objętych żądaniem — zakaz usuwania - Techniczny: zabezpieczenie logów Zone 4 z relevant time period (już immutable, ale dodatkowy snapshot) - NIE udostępniamy danych przed formalną analizą prawną

Eradykacja: - Nie dotyczy w klasycznym sensie. Procedura prawna prowadzona do rozstrzygnięcia.

Recovery: 1. Po rozstrzygnięciu: zniesienie litigation hold (jeśli zastosowany) 2. Komunikacja do klienta (jeśli gag order zniesiony) 3. Przegląd: czy żądanie ujawniło słabość w ochronie danych?

Komunikacja: - Legal: prowadzi całą komunikację z organami - Klient: powiadomiony gdy prawnie dopuszczalne (uwaga na gag orders) - Zarząd: informowany o każdym żądaniu prawnym - Regulator: FDPIC jeśli dotyczy danych osobowych (Szwajcaria) - Publiczna: NIE — chyba że wymaga tego prawo lub decyzja zarządu

Co SYLION może dostarczyć organom: - Logi Zone 4 (metadata, session logs, connection logs) - Logi CDR (file transfer metadata, hash records) - Logi administracyjne (management plane audit) - NIE MOŻE dostarczyć: treści komunikacji E2EE (Matrix — klucze są per-device), danych z terminala (thin client — brak danych), efemerycznych kluczy sesji (nie przechowywane)

Dowody do zachowania: - Kopia żądania prawnego - Analiza prawna i opinia Legal - Korespondencja z organami - Record of data provided (jeśli udostępniono) - Timeline procedury

Lessons learned checklist: - [] Czy procedura prawna zadziałała sprawnie? - [] Czy Legal był dostępny w wymaganym czasie? - [] Czy cross-jurisdiction była odpowiednio obsłużona? - [] Czy transparency report wymaga aktualizacji? - [] Czy potrzebne zmiany w data retention policy?

Rozdział 100. Forensics cyfrowe

Status: [N] Normatywny Odbiorca: SOC, IR Team, Forensic Analyst, Legal, CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 98, 99, 101, 42, 55

100.1 Zasady dowodowe

Forensics cyfrowe w SYLION muszą spełniać wymagania umożliwiające wykorzystanie dowodów w postępowaniach prawnych, audytach compliance i wewnętrznych dochodzeniach. Obowiązują następujące zasady:

Dopuszczalność (Admissibility): Dowody cyfrowe muszą być zbierane w sposób zapewniający ich dopuszczalność w postępowaniach sądowych w jurysdykcjach operacyjnych SYLION (Szwajcaria, USA, Polska, UE). Wymaga to: - Udokumentowanej procedury zbierania dowodów (standard operating procedure) - Weryfikowalnej integralności dowodów (hash SHA-256 w momencie zebrania) - Nieprzerwanego łańcucha dowodowego (chain of custody) - Zastosowania uznanych narzędzi i metod forensic (zgodnych z NIST SP 800-86, ISO 27037)

Integralność dowodów (Evidence Integrity): Zone 4 zapewnia natywną integralność dzięki WORM storage i hash chain. Dowody spoza Zone 4 muszą być zabezpieczone dodatkowym hashowaniem (SHA-256) w momencie zebrania, z timestampem z zaufanego źródła czasu (NTP serwer z certyfikatem).

Łańcuch dowodowy (Chain of Custody): Każda operacja na dowodach (zebranie, transfer, analiza, storage, udostępnienie) musi być udokumentowana w formularzu chain of custody (szczegóły w 100.8). Dowody nie mogą być modyfikowane — analiza prowadzona jest wyłącznie na kopiach forensycznych.

Proporcjonalność: Zbieranie dowodów musi być proporcjonalne do incydentu. Nie zbieramy więcej danych niż jest to uzasadnione celem śledztwa. Zbieranie danych objętych E2EE (treść komunikacji) jest technicznie niemożliwe bez kluczy urządzeń — i nie próbujemy tego obchodzić.

100.2 Co i gdzie zabezpieczać

Macierz źródeł dowodowych:

Źródło	Lokalizacja	Volatility	Wartość forensic	Dostępność
Logi Zone 4	WORM storage	Niska (immutable)	Najwyższa — źródło prawdy	Zawsze dostępne
Network captures	G1/G2, firewall	Wysoka (overwritten)	Wysoka	Zależna od konfiguracji retencji
Terminal artifacts	Terminal operatora	N/A	Minimalna — thin client, brak danych	Terminal nie przechowuje danych
HSM audit logs	Moduły HSM	Niska	Wysoka (operacje kryptograficzne)	Export via API
Management plane logs	Management API → Zone 4	Niska (persisted)	Wysoka (admin actions)	Zawsze dostępne
Firecracker VM state	Hypervisor host	Wysoka (destroyed on terminate)	Średnia do wysokiej	Tylko jeśli snapshot przed destroy
CDR processing logs	CDR pipeline → Zone 4	Niska (persisted)	Wysoka (file transfer evidence)	Zawsze dostępne
Matrix event logs	Homeserver → Zone 4	Niska (persisted)	Średnia (metadata, nie content)	Zawsze dostępne

Priorytet zabezpieczania (od najwyższego): 1. Zone 4 logs — zawsze dostępne, immutable, hash-chained → źródło prawdy 2. HSM audit logs — operacje kryptograficzne, key usage 3. Management plane logs — admin activity, policy changes 4. Network flow data — connection metadata, timing 5. CDR processing logs — file transfer evidence 6. Memory snapshots — tylko jeśli captured przed destroy

100.3 Log integrity

Procedura weryfikacji hash chain:

Zone 4 przechowuje logi w formie hash chain, gdzie każdy blok logów zawiera hash poprzedniego bloku. Weryfikacja integralności polega na:

Sequential hash verification: Pobranie bloków logów w kolejności chronologicznej i weryfikacja, że `hash(block[n-1]) == block[n].previous_hash`. Każda niezgodność wskazuje na manipulację lub lukę w logach.

WORM storage verification: Potwierdzenie, że storage backend Zone 4 jest w trybie WORM (Write Once Read Many) — żaden blok nie został nadpisany po zapisie. Weryfikacja timestamp'ów: czy bloki są w porządku chronologicznym?

Timestamp verification: Sprawdzenie, że timestamp'y bloków są spójne z NTP reference. Anomalie w timestampach (przeskoki, duplikaty, niezgodności z NTP) mogą wskazywać na manipulację.

Cross-reference verification: Porównanie logów Zone 4 z lokalnymi buforami komponentów (jeśli dostępne) — spójność timestamp'ów i zawartości.

Narzędzia weryfikacji: Weryfikacja hash chain musi być wykonywana za pomocą zwalidowanego narzędzia wewnętrznego (sylicon-logverify), którego integralność jest weryfikowana przed użyciem (code signing). Wynik weryfikacji jest sam logowany w Zone 4.

Periodic integrity checks: Automatyczna weryfikacja hash chain musi być wykonywana co 24 godziny. Wynik (pass/fail) jest monitorowany przez SIEM. Failure triggering: playbook 99.11 (degradacja SIEM).

100.4 Session evidence

Sesje w SYLION generują następujące artefakty forensic:

Session records: - Session ID (unique identifier) - Operator ID (who established the session) - Terminal ID (from which terminal) - Workload ID (which microVM) - Session start/end timestamps - Session broker used - Session type (desktop, voice, file transfer)

Connection logs: - IPsec SA establishment/teardown (timestamps, endpoints, cipher suite) - G1 routing (which G1 handled the session) - G2 policy decisions (what policies were evaluated, outcomes) - Network path (source → G1 → G2 → session broker → workload)

Policy decision logs: - Every policy evaluation by G2 for the session - Deny/allow decisions with rationale - Policy version at time of decision

Audio/video session metadata (nie content): - Session start/end time - Codec negotiated - Participants (operator IDs) - Duration - Quality metrics (jitter, latency, packet loss) - NIE przechowywana jest treść audio/video — szyfrowanie E2EE end-to-end

100.5 Network evidence

Firewall logs: Logi G1 i G2 zawierają: source/destination IP, port, protocol, action (allow/deny), timestamp, rule matched, bytes transferred. Przechowywane w Zone 4 z hash chain.

IPsec SA records: Każde ustanowienie Security Association jest logowane: IKEv2 handshake (initiator, responder, cipher suite negotiated, certificates used, timestamp). Teardown (reason, timestamp). Rekey events.

DNS query logs: Zapytania DNS generowane przez workloady i routery operatorów (jeśli routing przez SYLION DNS). Przechowywane: timestamp, source, query, response, TTL.

Flow data: NetFlow v9/IPFIX z G1/G2: source/destination, ports, protocol, bytes, packets, timestamps, flow duration. Retencja: 1 rok. Flow data pozwala na rekonstrukcję wzorców komunikacji bez dostępu do treści.

100.6 File transfer evidence

CDR processing logs: Każdy plik przechodzący przez Content Disarm and Reconstruction (CDR) generuje: - File hash (SHA-256) przed i po przetworzeniu CDR - File type detected (MIME type, magic bytes) - CDR actions performed (co zostało usunięte/zdezynfekowane) - Decision: pass/reject (z reason code) - Operator ID (who initiated transfer) - Timestamp (submission, processing start, processing end, delivery)

Staging zone artifacts: Pliki w staging zone CDR przechowywane są tymczasowo (configurable retention, default 24h). Na potrzeby forensic, staging zone może być zamrożona (hold) aby zachować pliki dłużej.

File hash records: Persistent record w Zone 4 zawierający hash każdego przetworzonego pliku, umożliwiający późniejszą weryfikację: czy ten plik przeszedł przez CDR? Kiedy? Z jakim wynikiem?

Delivery confirmation: Log potwierdzający dostarczenie pliku do operatora docelowego (lub reject z reason).

100.7 Admin activity evidence

Management plane audit trail: Każda operacja administracyjna jest logowana w Zone 4: - Admin ID (who) - Action performed (what) - Target (on what resource) - Timestamp (when) - Source IP / session ID (from where) - Result (success/failure) - Dual auth peer (who approved, if applicable)

Dual-auth records: Operacje wymagające dual authorization generują dodatkowy log: - Requestor (admin initiating) - Approver (second admin authorizing) - Action approved - Timestamp request → approval - Approval method (FIDO2, SMS fallback)

Break-glass usage: Każde użycie procedury break-glass jest logowane z: - Admin ID - Reason provided - Actions performed during break-glass session - Duration of break-glass session - Cleanup actions post break-glass - Mandatory post-incident review trigger

100.8 Chain of custody

Wymagania dokumentacyjne:

Formularz łańcucha dowodowego musi zawierać:

Pole	Opis
Evidence ID	Unikalny identyfikator dowodu (format: INC-YYYY-NNNN-EV-NN)
Evidence type	Typ dowodu (log extract, memory dump, config snapshot, network capture)
Hash (SHA-256)	Hash dowodu w momencie zebrania
Collection date/time	Timestamp zebrania (UTC)
Collected by	Imię, rola, ID pracownika osoby zbierającej
Collection method	Narzędzie i procedura użyta do zebrania
Storage location	Gdzie dowód jest przechowywany
Access log	Kto i kiedy uzyskał dostęp do dowodu

Procedura transferu dowodów: 1. Osoba przekazująca generuje hash dowodu i podpisuje cyfrowo 2. Osoba odbierająca weryfikuje hash i podpis 3. Transfer jest logowany w formularzu chain of custody 4. Oryginał pozostaje w Zone 4 (immutable) — transfer dotyczy kopii forensycznych 5. Kopie forensyczne przechowywane w dedykowanym, zaszyfrowanym storage z ograniczonym dostępem

Tamper-evident packaging: Dowody cyfrowe eksportowane na nośniki fizyczne (np. na potrzeby organów ścigania) muszą być: - Zasyfrowane (AES-256-GCM) - Opatrzono podpisem cyfrowym - Umieszczone na nośniku z tamper-evident seal - Udokumentowane w chain of custody

100.9 Granice forensic readiness w SYLION

Co SYLION MOŻE dostarczyć śledczym: - Metadata komunikacji: kto z kim komunikował się, kiedy, jak długo (z logów Zone 4) - Logi sesji: kiedy operator nawiązał sesję, z jakiego terminala, do jakiego workloadu - Logi CDR: jakie pliki były transferowane, hashe plików, decyzje CDR - Logi administracyjne: kto wykonał jakie operacje administracyjne - Policy decision logs: jakie decyzje autoryzacyjne podjął system - Network flow data: wzorce komunikacji (source, destination, volume, timing)

Czego SYLION NIE MOŻE dostarczyć: - Treść komunikacji E2EE — wiadomości Matrix są szyfrowane end-to-end kluczami per-device. Homeserver nie posiada kluczy deszyfrujących. Dostęp do treści wymagałby dostępu do klucza urządzenia operatora. - Dane z terminala — terminal jest thin clientem i nie przechowuje danych. Konfiskata terminala nie daje dostępu do danych operatora. - Efemeryczne klucze sesji — klucze sesyjne IPsec i session keys nie są przechowywane po zakończeniu sesji. Nie jest możliwe retrospektywne odszyfrowanie przechwyconych sesji. - Treść głosu/wideo — sesje audio/video są szyfrowane E2EE. Przechowywana jest tylko metadata (czas, uczestnicy, czas trwania, metryki jakości).

Jak komunikować te ograniczenia organom ścigania: SYLION musi transparentnie informować organy ścigania o swoich możliwościach i ograniczeniach technicznych. Przygotowany jest standardowy dokument „Forensic Capabilities Statement” (utrzymywany przez Legal + Engineering) opisujący: - Jakie dane SYLION przechowuje i może udostępnić - Jakich danych SYLION nie przechowuje i nie jest w stanie udostępnić (wraz z wyjaśnieniem technicznym) - Formaty danych eksportowych - Procedura legal request (jurysdykcyjna, formalna)

Dokument ten jest aktualizowany przy każdej zmianie architektury wpływającej na forensic readiness i udostępniany organom na ich żądanie.

Rozdział 101. Komunikacja kryzysowa i raportowanie

Status: [N] Normatywny Odbiorca: Incident Commander, CISO, Legal, PR, Account Management Wpływ na baseline: Krytyczny Powiązane rozdziały: 98, 99, 100, 102

101.1 Komunikacja wewnętrzna

Incident Command Structure:

Komunikacja wewnętrzna podczas incydentu podlega ścisłej strukturze dowodzenia. Każdy incydent P1 lub P2 musi mieć wyznaczonego Incident Commandera (IC), który jest jedynym punktem decyzyjnym i koordynacyjnym.

Struktura ról w trakcie incydentu: - Incident Commander (IC) — odpowiada za ogólne zarządzanie incydemtem, podejmuje decyzje o eskalacji, containment i recovery. Komunikuje się z zarządem. IC musi być osobą z certyfikacją IR Level 2+ (Rozdział 105.3). - Technical Lead (TL) — odpowiada za techniczne aspekty containment i eradykacji. Koordynuje zespoły SOC i Engineering. - Communications Lead (CL) — odpowiada za komunikację do klientów, partnerów i regulatorów. Koordynuje z Legal i PR. - Scribe — dokumentuje timeline incydentu w czasie rzeczywistym, rejestruje decyzje i działania.

Kanały komunikacji:

Podczas incydentu P1 musi zostać aktywowany dedykowany kryzysowy pokój Matrix (crisis room). Pokój ten: - Jest pre-provisionowany (nie tworzony ad-hoc podczas incydentu) - Ma ograniczony dostęp (tylko IR Team, IC, management) - Jest monitorowany i logowany w Zone 4 - Uwaga: Jeśli incydent dotyczy kompromitacji Matrix (playbook 99.7), crisis room musi być aktywowany na alternatywnym kanale (dedykowany Signal workload lub telekonferencja)

Hierarchia kanałów komunikacji: 1. Matrix crisis room (primary) — aktualizacje tekstowe, decyzje, koordynacja 2. Telekonferencja (voice bridge) — aktywowana dla P1, co 30 minut statusy 3. Secure email — formalne notyfikacje, dokumenty, raporty 4. SMS/pager — tylko do mobilizacji zespołu (nie do przekazywania szczegółów incydentu)

Update cadence:

Severity	Częstotliwość aktualizacji	Kanał	Odbiorcy
P1	Co 30 minut	Matrix crisis room + voice bridge	IR Team, CISO, CTO, CEO
P2	Co 1 godzinę	Matrix crisis room	IR Team, CISO
P3	Co 4 godziny	Matrix incident channel	SOC, IR Team
P4	Daily standup	Ticket system	SOC

Każda aktualizacja musi zawierać: obecny status, podjęte działania od ostatniej aktualizacji, planowane następne kroki, zmiana severity (jeśli dotyczy), ETA rozwiązania.

Bridge/call procedures: Telekonferencja kryzysowa musi mieć PIN dostępu znany tylko IR Team. Nagrywanie telekonferencji jest obowiązkowe i przechowywane w Zone 4. Telekonferencja prowadzona jest przez IC, z agendą: status update od TL → komunikacja update od CL → decyzje → next actions.

101.2 Komunikacja do klienta

Zasady komunikacji do klientów:

Klienci muszą być informowani o incydentach, które wpływają na ich operatorów lub dane. Komunikacja musi być: - Szybka — pierwsza notyfikacja w ciągu 1 godziny od klasyfikacji P1, 4 godzin od P2 - Jasna — język zrozumiały dla odbiorcy biznesowego, bez żargonu technicznego - Uczciwa — nie ukrywamy zakresu incydentu, ale nie ujawniamy wektorów ataku - Regularna — aktualizacje zgodnie z cadence (P1: co 1h, P2: co 4h)

Szablon pierwszej notyfikacji:

Temat: [SYLION Security Notification] Incydent wpływający na Państwa usługę Szanowni Państwo, Informujemy, że w dniu [DATA] o godzinie [CZAS] UTC zidentyfikowaliśmy incydent bezpieczeństwa wpływający na [OPIS KOMPONENTU/USŁUGI]. Co się wydarzyło: [KRÓTKI OPIS — co zaobserwowano, bez szczegółów wektora ataku] Wpływ na Państwa usługę: [KONKRETNY OPIS — co było niedostępne/zagrożone] Podjęte działania: [OGÓLNY OPIS — containment, recovery steps]

Obecny status: [AKTYWNY / ROZWIĄZANY / W TRAKCIE RECOVERY] Następna aktualizacja: [CZAS następnej komunikacji] W razie pytań prosimy o kontakt: [SECURITY CONTACT] Z poważaniem, SYLION Security Operations

Szablon aktualizacji:

Temat: [SYLION Security Update] Aktualizacja incydentu [ID] — [STATUS] Szanowni Państwo, Aktualizacja dotycząca incydentu [ID] z dnia [DATA]. Status: [AKTYWNY / ROZWIĄZANY / W TRAKCIE RECOVERY] Od ostatniej aktualizacji: [OPIS PODJĘTYCH DZIAŁAŃ] Wpływ: [AKTUALNY WPŁYW — czy sytuacja się poprawiła/pogorszyła] Następne kroki: [PLANOWANE DZIAŁANIA] Następna aktualizacja: [CZAS] Z poważaniem, SYLION Security Operations

Szablon notyfikacji o rozwiązaniu:

Temat: [SYLION Security Resolved] Incydent [ID] — Rozwiązany Szanowni Państwo, Informujemy, że incydent [ID] z dnia [DATA] został rozwiązany. Podsumowanie: [CO SIĘ WYDARZYŁO — krótkie podsumowanie] Czas trwania: [OD — DO] Wpływ: [KOŃCOWA OCENA WPŁYWU] Podjęte działania naprawcze: [OPIS DZIAŁAŃ ZAPOBIEGAJĄCYCH POWTÓRZENIU] Raport szczegółowy zostanie dostarczony w ciągu [5/10] dni roboczych. Z poważaniem, SYLION Security Operations

Komunikacja prowadzona jest przez Communications Lead we współpracy z Account Managerem klienta. Każda wiadomość do klienta musi być zatwierdzona przez IC i Legal (jeśli dotyczy danych osobowych lub obowiązków regulacyjnych).

101.3 Komunikacja do partnerów

Kiedy partnerzy muszą być powiadomieni:

Partnerzy wdrożeniowi (implementation partners) muszą być powiadomieni w następujących sytuacjach: - Incydent dotyczy klientów, których partner wdrożył lub obsługuje - Incydent dotyczy komponentu, za którego maintenance partner odpowiada - Incydent wymaga działań ze strony partnera (np. customer communication, on-site support) - Supply chain compromise dotyczy artefaktów dostarczanych przez partnera

Co udostępniamy partnerom: - Ogólny opis incydentu (zakres jak komunikacja do klienta) - Wpływ na ich klientów - Wymagane działania ze strony partnera - Timeline i ETA rozwiązania - NIE udostępniamy: szczegółów wektora ataku, wewnętrznych logów, informacji o innych klientach/partnerach

Kanał komunikacji: Dedykowany, szyfrowany kanał komunikacji z partnerami (partner Matrix room lub secure email). Komunikacja zgodna z umową partnerską (NDA, SLA).

Cadence: Taki sam jak komunikacja do klientów, z uwzględnieniem specyfiki partnera. Partner otrzymuje aktualizacje równolegle z klientem lub wcześniej (jeśli partner musi podjąć działania przed komunikacją do klienta).

101.4 Komunikacja do regulatora

GDPR Article 33 — Notyfikacja do organu nadzorczego (72 godziny):

W przypadku naruszenia ochrony danych osobowych, SYLION musi powiadomić właściwy organ nadzorczy w ciągu 72 godzin od stwierdzenia naruszenia. Notyfikacja musi zawierać: - Charakter naruszenia (jakie dane, ilu osób dotyczy, jakie kategorie) - Dane kontaktowe DPO / osoby kontaktowej - Prawdopodobne konsekwencje naruszenia - Środki podjęte lub proponowane w celu zaradzenia naruszeniu

Właściwy organ nadzorczy: - Swiss AG (primary entity): FDPIC (Federal Data Protection and Information Commissioner), Feldeggweg 1, CH-3003 Berne - Polish Sp. z o.o.: UODO (Urząd Ochrony Danych Osobowych), ul. Stawki 2, 00-193 Warszawa - Klienci w UE: Lead supervisory authority ustalana zgodnie z art. 56 GDPR (organ państwa, w którym znajduje się główna siedziba przetwarzającego/administratora) - US LLC: brak federalnego organu ochrony danych — notyfikacja stanowa per state data breach notification law

NIS2 — Obowiązki raportowania:

Jako dostawca usług cyfrowych/managed security, SYLION może podlegać obowiązkowi NIS2: - Early warning (24h): Wstępne powiadomienie do właściwego CSIRT w ciągu 24 godzin od wykrycia significant incident. Zawiera: charakter incydentu, wstępną ocenę, czy incydent ma potencjalnie transgraniczny wpływ. - Incident notification (72h): Pełna notyfikacja w ciągu 72 godzin: aktualizacja early warning, wstępna ocena severity i impact, indicators of compromise (IoC) jeśli dostępne. - Final report (1 miesiąc): Kompletny raport w ciągu 1 miesiąca od notyfikacji: szczegółowy opis incydentu, root cause, podjęte środki, transgraniczny wpływ (jeśli dotyczy).

Procedura decyzyjna: Legal + CISO wspólnie oceniają w ciągu 12 godzin od wykrycia incydentu, czy zachodzą przesłanki do notyfikacji regulatora. Decyzja dokumentowana jest w incydent record i podlega przeglądowi zarządu.

101.5 Komunikacja publiczna

Kiedy publiczna komunikacja jest wymagana/właściwa: - Regulacja wymaga publicznego ujawnienia (np. gdy naruszenie dotyczy dużej liczby osób) - Incydent jest publicznie widoczny (usługa niedostępna, media donoszą) - Proaktywna transparentność jest strategicznie uzasadniona (budowanie zaufania) - Klient zażądał publicznego oświadczenia

Kiedy NIE komunikować publicznie: - Incydent jest w fazie containment i publiczna komunikacja mogłaby pomóc atakującemu - Legal zaleca powstrzymanie się (toczące się postępowanie) - Brak wpływu na zewnętrznych interesariuszy

Szablon oświadczenia prasowego:

SYLION AG — Oświadczenie dot. incydentu bezpieczeństwa W dniu [DATA] SYLION zidentyfikował i zareagował na incydent bezpieczeństwa dotyczący [OGÓLNY OPIS KOMPONENTU]. Co wiemy: - [FAKT 1] - [FAKT 2] Co zrobiliśmy: - [DZIAŁANIE 1] - [DZIAŁANIE 2] Co nie zostało naruszone: - [ELEMENT NIENARUSZONY — np. "Treść komunikacji E2EE pozostała bezpieczna"] Dalsze kroki: - [PLANOWANE DZIAŁANIA] Będziemy informować o postępach. Dodatkowe informacje: [KONTAKT]

Czego NIE ujawniać: - Szczegółowe wektory ataku (mogą być wykorzystane przez innych atakujących) - Nazwy klientów dotkniętych incydem (chyba że klient wyraźnie zgodzi się) - Szczegóły techniczne infrastruktury - Spekulacje na temat atrybucji atakującego (chyba że potwierdzone przez organy ścigania)

Każde publiczne oświadczenie musi być zatwierdzone przez: CEO + Legal + CISO. Komunikację publiczną prowadzi wyznaczony rzecznik (Media Spokesperson), nie IC ani TL.

101.6 Raporty incydentowe

Struktura raportu post-incydentowego:

Każdy incydent P1 i P2 musi mieć kompletny raport post-incydentowy. Dla P3 — raport jest rekomendowany. Raport musi być ukończony w ciągu: - P1: 10 dni roboczych od zamknięcia incydentu - P2: 15 dni roboczych - P3: 20 dni roboczych

Sekcje raportu:

Executive Summary (max 1 strona):

Klasyfikacja incydentu (severity, type)

Daty: detection, triage, containment, resolution

Wpływ: kto dotknięty, co niedostępne/zagrożone, jak długo

Status: rozwiązany, action items w toku

Timeline (chronologiczny opis):

Format: [TIMESTAMP UTC] — [ZDARZENIE] — [OSOBA/SYSTEM]

Od pierwszego alertu/zdarzenia do zamknięcia incydentu

Dokładność co do minuty dla P1, co do godziny dla P2/P3

Impact Assessment:

Liczba dotkniętych operatorów/klientów

Czas niedostępności usługi (downtime)

Czy dane były zagrożone/naruszone? Jakie kategorie?

Wpływ finansowy (szacunkowy)

Wpływ reputacyjny

Root Cause Analysis (RCA):

Bezpośrednia przyczyna (co spowodowało incydent)

Przyczyna źródłowa (dlaczego to było możliwe)

Contributing factors

Diagram: chain of events

Actions Taken:

Containment (co, kiedy, kto)

Eradication (co, kiedy, kto)

Recovery (co, kiedy, kto)

Communication (do kogo, kiedy, co)

Lessons Learned:

Co zadziałało dobrze

Co nie zadziałało

Rekomendacje zmian (architektura, procedury, szkolenia)

Playbooki do aktualizacji

Action Items:

Lista działań korygujących z: owner, deadline, priority

Tracking ID dla każdego action item

Zatwierdzenie raportu: - P1: CISO + CTO + IC - P2: CISO + IC - P3: SOC Manager

Raporty przechowywane w Zone 4 z retencją 5 lat.

101.7 Szablony raportów i timeline'y

Timeline tracking template:

Podczas trwania incydentu, Scribe prowadzi live timeline w następującym formacie:

```
# Incident Timeline — [INCIDENT_ID] # Severity: [P1/P2/P3/P4] # Incident Commander: [IMIĘ] # Status: [ACTIVE/RESOLVED/CLOSED] [YYYY-MM-DD HH:MM UTC]
[ALERT] — SIEM alert: [opis alertu] [YYYY-MM-DD HH:MM UTC] [TRIAGE] — [ANALYST] — Rozpoczęto triage [YYYY-MM-DD HH:MM UTC] [TRIAGE] — [ANALYST] —
Skasifikowano jako [SEVERITY] [YYYY-MM-DD HH:MM UTC] [ESCALATION] — IC wyznaczony: [IMIĘ] [YYYY-MM-DD HH:MM UTC] [CONTAINMENT] — [OSOBA] —
[OPIS DZIAŁANIA] [YYYY-MM-DD HH:MM UTC] [DECISION] — IC: [OPIS DECYZJI] [YYYY-MM-DD HH:MM UTC] [COMMUNICATION] — [OSOBA] — Wysłano
notyfikację do [ODBIORCA] [YYYY-MM-DD HH:MM UTC] [ERADICATION] — [OSOBA] — [OPIS DZIAŁANIA] [YYYY-MM-DD HH:MM UTC] [RECOVERY] — [OSOBA] —
[OPIS DZIAŁANIA] [YYYY-MM-DD HH:MM UTC] [RESOLVED] — Usługa przywrócona [YYYY-MM-DD HH:MM UTC] [CLOSED] — Incydent zamknięty
```

Notification template registry:

Szablony notyfikacji przechowywane są w repozytorium z wersjonowaniem: - notification_customer_initial.md — pierwsza notyfikacja klienta - notification_customer_update.md — aktualizacja dla klienta - notification_customer_resolved.md — notyfikacja o rozwiązaniu - notification_regulator_gdpr_72h.md — notyfikacja GDPR Art. 33 - notification_regulator_nis2_24h.md — NIS2 early warning - notification_regulator_nis2_72h.md — NIS2 pełna notyfikacja - notification_regulator_nis2_final.md — NIS2 raport końcowy - notification_partner.md — notyfikacja partnera - notification_public_statement.md — oświadczenie publiczne - report_post_incident.md — szablon raportu post-incydentowego

Każdy szablon musi mieć: autora, datę ostatniej aktualizacji, wersję, listę zmiennych do wypełnienia ([PLACEHOLDER]), oraz notatkę prawną (legal disclaimer) zatwierdzoną przez Legal.

Szablony przeglądane są kwartalnie przez Legal + CISO + Communications Lead. Aktualizacja szablonu wymaga zatwierdzenia Legal.

Rozdział 102. Lessons learned i ciągłe doskonalenie

Status: [N] Normatywny Odbiorca: IR Team, Engineering, Product, SOC, CISO, Training Lead Wpływ na baseline: Wysoki Powiązane rozdziały: 98, 99, 101, 103, 105

102.1 Feed-back loop do architektury

Incydenty stanowią najcenniejsze źródło informacji o rzeczywistych słabościach architektury. Każdy incydent P1 i P2 musi wygenerować ocenę wpływu architektonicznego w ramach sesji lessons learned.

Proces: 1. Podczas sesji lessons learned, Technical Lead identyfikuje architectural root causes (np. „brak redundancji G1 w regionie X”, „brak rate limiting na management API”) 2. Każda zidentyfikowana słabość architektoniczna jest dokumentowana jako Architecture Decision Record (ADR) proposal (format ADR: Rozdział 103.3) 3. ADR proposal jest tagowany jako incident-driven i priorytetyzowany: - Security-critical: Fast-track review — ADR musi być zatwierdzony w ciągu 5 dni roboczych, implementacja w ciągu 30 dni - Security-important: Standard review — ADR w ciągu 15 dni, implementacja w ciągu kwartału - Improvement: Dodany do backlogu architektonicznego

Fast-track process dla zmian security-critical: - ADR proposal od Technical Lead (author) + CISO (sponsor) - Review przez Architecture Board w ciągu 48 godzin (tryb pilny) - Implementacja z dedykowanym sprint/zespołem - Weryfikacja: test exploitability — czy zmiana faktycznie eliminuje wektor ataku?

Tracking: Każdy incident-driven ADR ma powiązanie z incydem (Incident ID). Postęp implementacji jest raportowany na monthly security review. ADR niezaimplementowane w terminie eskalowane do CTO.

Metryka: „Incident-to-ADR time” — czas od zamknięcia incydentu do zatwierdzenia ADR. Target: <15 dni roboczych dla security-critical.

102.2 Feed-back loop do produktu

Incydenty mogą ujawnić potrzeby produktowe — brak funkcji, niedostateczne kontrole, problemy z usability, które przyczyniły się do incydentu lub utrudniły response.

Proces: 1. Podczas lessons learned, Communications Lead i Account Manager identyfikują product-impacting findings (np. „operator nie wiedział, jak zgłosić utratę terminala — brak widocznego przycisku”, „CDR odrzucił plik, ale komunikat błędu był niezrozumiały”) 2. Każde finding jest dokumentowane jako product backlog item tagowany incident-driven 3. Product Owner priorytetyzuje item w backlogu 4. Jeśli finding dotyczy bezpieczeństwa (np. „brak alertu gdy operator transferuje nietypowo duży plik”) — fast-track priorytetyzacja

Security debt tracking: Zidentyfikowane słabości produktowe, które wynikają z kompromisów w implementacji (np. „monitoring file transfer volumes nie jest zaimplementowany — był w backlogu od Q2”), są tagowane jako security-debt. Security debt jest raportowany na quarterly security review i podlega osobnemu priorytetowi.

Metryka: „Security-debt-to-resolution time” — czas od zidentyfikowania security debt do implementacji fix. Target: <90 dni dla high severity, <180 dni dla medium.

102.3 Feed-back loop do procedur

Każdy incydent testuje procedury reagowania. Lessons learned muszą obejmować ocenę skuteczności użytego playbooku i ogólnych procedur IR.

Proces: 1. Incident Commander i Scribe oceniają: czy playbook był aktualny? Czy kroki były wykonalne? Czy czegoś brakowało? 2. Zidentyfikowane braki/ulepszenia dokumentowane jako playbook change request 3. Change request review przez IR Lead w ciągu 10 dni roboczych 4. Zatwierdzony change wdrażany do playbooku i wersjonowany (git commit z ID incydentu) 5. Zaktualizowany playbook jest dystrybuowany do SOC/IR Team i uwzględniany w kolejnej sesji szkoleniowej

Runbook improvements: Analogicznie do playbooków, runbooki operacyjne (Rozdział 104) są oceniane po incydentach dostępności i aktualizowane na podstawie doświadczeń.

Metryka: - „Playbook accuracy” — % kroków playbooku, które nie wymagały modyfikacji podczas rzeczywistego incydentu. Target: >90% - „Playbook update cadence” — średni czas od incydentu do aktualizacji playbooku. Target: <15 dni roboczych

102.4 Feed-back loop do szkoleń

Incydenty ujawniają luki w kompetencjach i przygotowaniu zespołów. Każda sesja lessons learned musi ocenić, czy zespół był odpowiednio przeszkolony.

Proces: 1. IC i TL oceniają: czy analitycy SOC poprawnie wykonali triage? Czy IR Team znał procedury? Czy operatorzy wiedzieli, jak zgłosić problem? 2. Zidentyfikowane luki kompetencyjne dokumentowane jako training gap 3. Training Lead (Rozdział 105) wdraża: - Aktualizację materiałów szkoleniowych - Dodatkowe ćwiczenia (drills) adresujące konkretny scenariusz - Jeśli luka krytyczna: obowiązkowe szkolenie korygujące w ciągu 30 dni

Ćwiczenia i symulacje triggerowane przez incydenty: Po każdym incydencie P1 musi zostać przeprowadzona symulacja tego scenariusza w ciągu 60 dni (z udziałem innego zespołu niż ten, który obsługiwał oryginalny incydent). Celem jest weryfikacja, że lekcje zostały przyswojone i playbook zaktualizowany.

Metryka: - „Training-gap-to-drill time” — czas od zidentyfikowania luki do przeprowadzenia ćwiczenia. Target: <60 dni - „Drill pass rate” — % ćwiczeń zakończonych sukcesem (containment w SLA). Target: >85%

102.5 Feed-back loop do compliance

Incydenty mogą ujawnić słabości w posturze compliance: niewystarczające kontrole, braki w dokumentacji, nieaktualne polityki.

Proces: 1. Legal i Compliance Officer oceniają wpływ incydentu na compliance posture: - Czy procedury GDPR/NIS2 zadziałały? - Czy notyfikacje do regulatora zostały wysłane terminowo? - Czy dowody zostały zabezpieczone zgodnie z wymogami? - Czy incydent ujawnił nowe obowiązki regulacyjne? 2. Zidentyfikowane braki dokumentowane jako compliance finding 3. Compliance finding podlega procesowi remediation z deadline i owner

Control effectiveness reassessment: Po incydencie P1, kontrole bezpieczeństwa powiązane z wektorem ataku muszą zostać ponownie ocenione: - Czy kontrola istniała i zadziałała? (effective) - Czy kontrola istniała ale nie zadziałała? (ineffective — wymaga naprawy) - Czy kontrola nie istniała? (gap — wymaga wdrożenia) Wynik reassessment dokumentowany w risk register i raportowany na quarterly compliance review.

Audit readiness: Po każdym incydencie P1/P2, dokumentacja incydentu (raport, dowody, chain of custody, notyfikacje) musi być skompletowana w formie gotowym do audytu (audit-ready package). Package zawiera: raport post-incydentowy, timeline, dowody, komunikację, action items z tracking.

102.6 Zamknięcie działań po incydencie

Action tracking:

Każdy action item z lessons learned musi mieć: - Owner — imiennie wyznaczona osoba odpowiedzialna - Deadline — realistyczny termin, zatwierdzony przez ownera i IC - Priority — Critical (30 dni), High (60 dni), Medium (90 dni), Low (180 dni) - Status — Open, In Progress, Verification, Closed - Verification criteria — jak potwierdzić, że action item jest zrealizowany

Workflow zamknięcia: 1. Owner implementuje zmianę 2. Owner ustawia status „Verification” 3. Weryfikator (nie owner) potwierdza implementację: - Dla zmian architektonicznych: Architecture Board member - Dla zmian proceduralnych: IR Lead - Dla zmian szkoleniowych: Training Lead - Dla zmian compliance: Compliance Officer 4. Weryfikator zatwierdza — status „Closed”

Eskalacja: Action items przekraczające deadline eskalowane są automatycznie: - +7 dni: notyfikacja do ownera i jego managera - +14 dni: eskalacja do CISO - +30 dni: eskalacja do CTO/CEO Nie dopuszcza się zamknięcia incydentu (w sensie organizacyjnym) jeśli istnieją otwarte Critical action items.

Raportowanie: - Weekly: lista otwartych action items (IR Team meeting) - Monthly: metrics dashboard (% action items closed on time, average resolution time) - Quarterly: comprehensive review (trendy, recurring issues, systemic improvements needed)

Metryka sumaryczna: - „Action item on-time completion rate” — Target: >90% - „Mean time to remediation (MTTR)” — od lessons learned do zamknięcia action item - „Recurring incident rate” — % incydentów tego samego typu po wdrożeniu corrective actions. Target: 0% (same root cause powinno skutkować brakiem powtórzeń)

Rozdział 103. Dokumentacja deweloperska i techniczna

Status: [N] Normatywny Odbiorca: Engineering, DevOps, Technical Writers, Architecture Board Wpływ na baseline: Wysoki Powiązane rozdziały: 5, 104, 105, 106

103.1 Doc style guide

Dokumentacja SYLION musi spełniać rygorystyczne standardy jakości, spójności terminologicznej i dostępności. Poniższy style guide obowiązuje wszystkich autorów dokumentacji — zarówno Engineering, jak i Technical Writers.

Standardy pisania: - Język techniczny: precyzyjny, jednoznaczny, bez żargonu potocznego - Strona czynna preferowana nad bierną (np. „Administrator wykonuje rotację kluczy” zamiast „Rotacja kluczy jest wykonywana”) - Zdania krótkie — maksymalnie 25 słów. Jedno zdanie = jeden koncept - Instrukcje w formie ponumerowanych kroków (1, 2, 3...), nie akapitów opisowych - Każdy dokument musi mieć jasno określonego odbiorcę (audience) w nagłówku

Spójność terminologiczna: Terminologia SYLION jest zdefiniowana w rozdziale 5 (Glosariusz) niniejszej Księgi. Obowiązują następujące zasady: - Każdy termin techniczny musi być używany konsekwentnie — jedno pojęcie = jedna nazwa - Zakazane są synonimy (np. nie wolno używać zamiennie „terminal” i „endpoint” — obowiązuje „terminal”) - Nowe terminy muszą być dodane do Glosariusza przed użyciem w dokumentacji - Automatyczna walidacja terminologii: linter sprawdzający zgodność z Glosariuszem w pipeline CI/CD

Standardy diagramów: - Narzędzia: PlantUML (preferowane dla sequence diagrams, component diagrams) lub Mermaid (dla flowcharts, state diagrams) - Diagramy muszą być generowane z kodu (nie z narzędzi WYSIWYG) — umożliwia wersjonowanie i diff - Każdy diagram musi mieć: tytuł, legendę (jeśli >3 elementów), datę ostatniej aktualizacji - Styl: czarno-biały z jednym kolorem akcentowym (SYLION teal). Brak 3D, cieni, gradientów - Diagramy architektoniczne muszą być spójne z diagramami w Księdze

Wymagania dotyczące code samples: - Każdy code sample musi być testowalny (copy-paste → run without modification) - Język przykładów: Python (primary), cURL (API calls), Bash (operations) - Każdy sample opatrzony komentarzami wyjaśniającymi kluczowe decyzje - Samples wersjonowane razem z API — automatyczna weryfikacja w CI/CD (contract testing)

Proces review: 1. Autor tworzy dokument w repozytorium dokumentacji (Git) 2. Pull request z tagiem typu dokumentu (API, runbook, ADR, guide) 3. Review: Technical Writer (styl, spójność) + SME (dokładność techniczna) 4. Merge po dwóch approvals 5. Automatyczna publikacja do documentation portal

103.2 Reference docs

Dokumentacja referencyjna obejmuje trzy kategorie i w miarę możliwości jest generowana automatycznie z kodu lub schematów, minimalizując ryzyko rozbieżności między dokumentacją a implementacją.

API reference: - Generowana automatycznie z OpenAPI spec (Rozdział 103.4) - Każdy endpoint: opis, parametry, request/response examples, error codes - Wersjonowana per API version - Searchable online (documentation portal z wyszukiwarką full-text)

Component reference: - Każdy komponent SYLION (G1, G2, session broker, CDR, Matrix homeserver, Firecracker microVM, HSM) ma dedykowaną stronę referencyjną zawierającą: - Opis funkcji komponentu - Interfejsy (API, network, management) - Konfiguracja (parametry, domyślne wartości, dopuszczalne zakresy) - Zależności (od jakich komponentów zależy, jakie komponenty od niego zależą) - Metryki monitoringu (jakie metryki emituje, progi alertów) - Link do relevant ADRs

Configuration reference: - Kompletna lista wszystkich parametrów konfiguracyjnych systemu - Generowana automatycznie z configuration schema (JSON Schema / YAML schema) - Każdy parametr: nazwa, typ, domyślna wartość, dopuszczalny zakres, opis, wpływ na bezpieczeństwo (jeśli dotyczy) - Wersjonowana per release - Zmiany w parametrach konfiguracyjnych automatycznie generują changelog

103.3 Architecture Decision Records (ADR)

ADR dokumentują kluczowe decyzje architektoniczne, ich kontekst, rozważane alternatywy i konsekwencje. W SYLION ADR stanowią most między Księgą systemu a implementacją.

Szablon ADR:

ADR-[NUMER]: [TYTUŁ DECYZJI] ## Status [Proposed | Accepted | Deprecated | Superseded by ADR-XXX] ## Kontekst [Dlaczego ta decyzja jest potrzebna? Jaki problem rozwiązuje?] ## Decyzja [Co zdecydowaliśmy?] ## Rozważane alternatywy ### Alternatywa A: [NAZWA] [Opis, plusy, minusy] ### Alternatywa B: [NAZWA] [Opis, plusy, minusy] ## Konsekwencje ### Pozytywne - [konsekwencja 1] ### Negatywne - [konsekwencja 1] ## Powiązania - Księga SYLION: Rozdział [X.Y] - Incydent (jeśli incident-driven): [INC-YYYY-NNNN] - Związane ADR: [ADR-XXX] ## Autorzy i zatwierdzenie - Autor: [IMIĘ] - Reviewer: [IMIĘ] - Zatwierdzenie: Architecture Board, [DATA]

Proces review: 1. Autor (zazwyczaj Tech Lead lub Principal Engineer) tworzy ADR proposal 2. Review przez Architecture Board (minimum 3 członków) 3. Jeśli incident-driven z tagiem security-critical: fast-track review 48h 4. Zatwierdzenie: consensus Architecture Board 5. Publikacja w ADR registry (searchable)

Searchable registry: ADR przechowywane są w repozytorium Git z indeksem searchable (documentation portal). Każdy ADR jest tagowany: component, security-impact, incident-driven, status. Wyszukiwanie po: tagu, pełnym tekście, numerze, autorze.

Linkowanie do Księgi: Każdy ADR musi wskazywać rozdziały Księgi, których dotyczy. Przy aktualizacji Księgi, powiązane ADR są przeglądane pod kątem aktualności.

103.4 API docs

OpenAPI publishing: Każde API SYLION musi mieć specyfikację OpenAPI 3.1 (lub nowszą). Specyfikacja jest źródłem prawdy dla: - Generowania dokumentacji referencyjnej - Contract testing (automatyczna weryfikacja zgodności implementacji ze specyfikacją) - SDK generation (klienckie biblioteki per język) - Mock server (do testów integracyjnych partnerów)

Versioning: API wersjonowane jest zgodnie z semver: - Major (v1 → v2): breaking changes — deprecation period minimum 12 miesięcy - Minor (v1.1 → v1.2): new features, backward compatible — announcement 30 dni przed - Patch (v1.1.1 → v1.1.2): bug fixes — changelog only

Aktywne wsparcie: current version + previous major version. Starsze wersje: security fixes only przez 6 miesięcy, potem sunset.

Sandbox environment: Dla partnerów i integratorów dostępne jest środowisko sandbox (non-production) umożliwiające: - Testowanie integracji API - Weryfikacja flow uwierzytelniania - Symulacja scenariuszy błędów - Sandbox nie zawiera danych produkcyjnych i ma rate limiting

Change notifications: Zmiany w API komunikowane są: - Changelog w repozytorium dokumentacji (automatycznie z diff OpenAPI spec) - Email notification do zarejestrowanych integratorów (30 dni przed breaking changes) - Deprecation warnings w response headers (API zwraca header Deprecation: true dla deprecated endpoints)

103.5 Runbooks

Runbooki to wykonywalne procedury krok-po-kroku dla operacji administracyjnych i utrzymaniowych. Różnią się od playbooków (Rozdział 99) tym, że dotyczą operacji planowanych, nie incydentów.

Format: Każdy runbook musi zawierać: - Tytuł i identyfikator (RB-XXXX) - Cel (co runbook realizuje) - Wymagania wstępne (uprawnienia, dostęp, narzędzia) - Procedura krok-po-kroku (ponumerowane kroki, z expected output na każdym kroku) - Weryfikacja sukcesu (jak potwierdzić, że operacja się powiodła) - Procedura rollback (jeśli operacja nie powiodła się) - Szacowany czas wykonania - Owner (kto jest odpowiedzialny za runbook)

Ownership: Każdy runbook ma wyznaczonego ownera (imiennie). Owner jest odpowiedzialny za: - Aktualność runbooka (przegląd po każdej zmianie komponentu) - Testowanie runbooka (co kwartał — dry run lub actual execution w staging) - Przegląd po incydencie (jeśli runbook był użyty lub powinien być użyty)

Testing cadence: - Runbooki krytyczne (DR, break-glass, key ceremony): testowane co kwartał - Runbooki operacyjne (upgrade, provisioning): testowane co pół roku - Test results logowane i raportowane na monthly ops review

Storage: Runbooki przechowywane w repozytorium Git (version-controlled), publikowane na documentation portal. Access control: runbooki zawierające sensitive procedures (break-glass, key ceremony) mają restricted access (SOC/IR/Admin only).

103.6 Security docs

Dokumentacja bezpieczeństwa wymaga szczególnej ostrożności w zakresie kontroli dostępu — ujawnienie informacji o zagrożeniach lub hardening gaps może ułatwić atak.

Threat model access control: - Threat model SYLION (STRIDE/DREAD analysis) jest dokumentem classified - Dostęp: Security Team, Architecture Board, CISO, CTO - Nie udostępniany partnerom ani klientom (streszczenie w formie security white paper — tak) - Przechowywany w zaszyfrowanym repozytorium z audit trail dostępu

CVE response documentation: - Dla każdej CVE dotyczącej komponentów SYLION: vulnerability assessment document - Zawiera: CVE ID, affected components, CVSS score, exploitability in SYLION context, mitigation/fix, timeline - Status tracking: Open → Assessed → Mitigated → Closed - Security advisory (publiczny jeśli dotyczy klientów): opis, wpływ, recommended actions

Security hardening guides: Per-component hardening guide: - G1/G2: minimal ACL, certificate pinning, firmware integrity check - Matrix homeserver: federation restrictions, E2EE enforcement, device verification policy - Firecracker: seccomp profiles, jailer configuration, resource limits - Router: kill switch configuration, DNS leak prevention, split tunnel prohibition - HSM: key usage policies, audit logging configuration, physical security requirements - Każdy guide wersjonowany i testowany przy każdym release

103.7 Integration guides

Dla każdej obsługiwanej integracji (API consumer, SDK user, webhook receiver) musi istnieć dedykowany przewodnik integracyjny.

Struktura per integration: 1. Opis integracji — co integracja umożliwia, jakie use cases 2. Authentication setup — krok-po-kroku konfiguracja uwierzytelniania (API key, OAuth 2.0, mTLS — zależnie od integracji) 3. Quick start — minimalny przykład „Hello World” (< 10 minut do first successful call) 4. Full API walkthrough — wszystkie dostępne operacje z przykładami 5. Sample code — kompletne, testowalne przykłady (Python, cURL, SDK) 6. Webhooks — konfiguracja, payloady, retry policy, verification (HMAC signatures) 7. Error handling — common errors, resolution steps, retry strategies 8. Rate limits — per-endpoint limits, burst limits, rate limit headers 9. Troubleshooting — FAQ specyficzne dla integracji 10. Changelog — historia zmian w integracji

Każdy integration guide testowany jest end-to-end przy każdym release API (automated integration tests). Sample code jest częścią test suite.

103.8 Versioned docs

Strategia wersjonowania dokumentacji:

Dokumentacja SYLION jest wersjonowana razem z oprogramowaniem: - Każdy release (major/minor) generuje nową wersję dokumentacji - Documentation portal wyświetla: current version (default), previous versions (dropdown) - URL scheme: docs.sylion.ch/v3.2/..., docs.sylion.ch/latest/...

Legacy version maintenance: - Current version: full maintenance (updates, corrections, improvements) - Current - 1 (previous major): security-related updates only - Older versions: frozen, z bannerem „This version is no longer maintained”

Sunset policy: - Documentation for deprecated API versions: maintained 6 miesięcy po sunset API - Potem: archived (dostępne na żądanie, nie w portalu) - Archive format: static HTML export + PDF

Diff between versions: Documentation portal powinien umożliwiać porównanie dokumentacji między wersjami (diff view) — szczególnie ważne dla klientów migrujących.

Rozdział 104. Przewodniki administracyjne i operacyjne

Status: [N] Normatywny Odbiorca: Administratorzy, Ops Team, SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 98, 99, 103, 105

104.1 Onboarding admina

Nowy administrator SYLION nie może wykonywać operacji uprzywilejowanych przed ukończeniem pełnego procesu onboardingowego. Proces obejmuje:

Provisioning dostępu (dzień 1–2): 1. Weryfikacja tożsamości (in-person lub video call z ID verification) 2. Utworzenie konta administracyjnego w IAM (przez istniejącego admina z dual authorization) 3. Wydanie FIDO2 token (hardware security key) — enrollment supervised 4. Przypisanie ról i uprawnień (principle of least privilege — minimum wymagany dostęp) 5. Konfiguracja terminala administracyjnego

Szkolenie obowiązkowe (dzień 3–5): Przed pierwszą operacją uprzywilejowaną, admin musi ukończyć: 1. Szkolenie podstawowe: architektura SYLION, model Zero Trust, role i odpowiedzialności (4h) 2. Szkolenie administracyjne: IAM, policy management, monitoring (8h) 3. Szkolenie IR: procedury incydentowe, playbooki, break-glass (4h) 4. Szkolenie compliance: GDPR, NIS2, obowiązki raportowe (2h) 5. Egzamin kompetencyjny (Rozdział 105.6) — wymagane minimum 80% poprawnych odpowiedzi

Okres mentorski (tydzień 2–4): Przez pierwsze 3 tygodnie po ukończeniu szkolenia, nowy admin pracuje pod nadzorem senior admina: - Wszystkie operacje uprzywilejowane wykonywane z mentorem jako second pair of eyes - Mentor zatwierdza dual auth requests nowego admina - Po 3 tygodniach: mentor assessment — jeśli pozytywny, admin przechodzi do samodzielnej pracy

Dokumentacja onboardingowa: Każdy onboarding jest dokumentowany: data ukończenia szkolenia, wynik egzaminu, data zakończenia mentorstwa, podpis mentora. Dokumentacja przechowywana w HR/IAM z retencją do 2 lat po offboardingu.

104.2 Daily ops checklist

Codziennie rano (do 10:00 czasu lokalnego), administrator dyżurny musi wykonać następujące czynności kontrolne:

Morning checks: - [] Sprawdzenie dashboardu SIEM: czy w ciągu ostatnich 24h wystąpiły nieopracowane alerty? - [] Sprawdzenie statusu wszystkich komponentów: G1, G2, session broker, Matrix, CDR — all green? - [] Sprawdzenie health check poszczególnych regionów - [] Przegląd logów Zone 4: czy ingestion rate jest na normalnym poziomie?

Alert review: - [] Przegląd alertów P3/P4, które nie wymagały natychmiastowej reakcji - [] Weryfikacja false positives: czy alert tuning jest potrzebny? - [] Sprawdzenie czy istnieją alerty w stanie „acknowledged” dłużej niż 24h

Backup verification: - [] Sprawdzenie statusu nocnych zadań backupowych (all success?) - [] Weryfikacja, że backup replication do secondary storage zakończyła się poprawnie - [] Sprawdzenie free space na backup storage

Certificate expiry check: - [] Przegląd dashboard certyfikatów: czy jakiegokolwiek certyfikat wygasa w ciągu 30 dni? - [] Jeśli tak: zainicjowanie procedury renewal

Wynik: Checklist jest logowany w systemie ops (timestamp, admin ID, wynik per punkt). Pominięcie checklist generuje alert do SOC Manager.

104.3 Weekly ops checklist

Co tydzień (piątek, do 14:00) administrator operacyjny przeprowadza rozszerzony przegląd:

Security scan review: - [] Przegląd wyników vulnerability scan (jeśli wykonywany tygodniowo) - [] Ocena nowych CVE dotyczących komponentów SYLION (SBOM watch) - [] Sprawdzenie: czy pending security patches czekają na deployment?

Capacity check: - [] Compute utilization per region (CPU, RAM, storage) - [] Network bandwidth utilization - [] License utilization (liczba aktywnych operatorów vs limit) - [] Prognoza: czy w ciągu 30 dni potrzebne będzie skalowanie?

DR readiness check: - [] Sprawdzenie statusu replikacji między regionami - [] Weryfikacja, że failover endpoint jest dostępny (health check secondary region) - [] Sprawdzenie: czy konfiguracja DR jest aktualna (ostatnia zmiana vs ostatni DR test)?

Patch status: - [] Lista pending patches per komponent - [] Ocena priorytetów: security patches → stability patches → feature patches - [] Zaplanowanie maintenance window jeśli potrzebny

Wynik: Raport tygodniowy zapisywany w systemie ops. Wyniki z anomaliami eskalowane do Ops Manager na poniedziałkowym standup.

Checklisty rytmu operacyjnego SOC

CODZIENNIE (każdy dyżurny SOC): [1] Przegląd alertów SIEM — priorytety P1/P2 nierozwiązane z poprzedniej doby. [2] Status gateway G1/G2 — healthcheck, latencja, packet loss. [3] Błędy provisioningu — pipeline IaC status. [4] Pliki w kwarantannie CDR — decyzja politykowa. [5] Nieudane logowania >5x na konto w ciągu 1h — analiza i eskalacja. [6] Status backupów — kompletność i hash integrity. [7] Certyfikaty wygasające <30 dni — inicjacja odnowienia. [8] Dead Man Switch status — weryfikacja że heartbeaty aktywne.

TYGODNIOWO (co poniedziałek): [1] Przegląd zmian konfiguracji ostatniego tygodnia (change log). [2] Weryfikacja aktywnych dostępów operatorów i administratorów — czy wszystkie są uzasadnione. [3] Test randomowej ścieżki odtworzenia (chaos engineering — 1 środowisko). [4] Aktualizacje bezpieczeństwa — status patchowania komponentów (target: CVSS ≥7.0 w <72h). [5] Drift polityk egress — czy whitelisty ASN są aktualne. [6] Symulacja Dead Man Switch (timeout test w środowisku testowym).

MIESIĘCZNIE (pierwszy wtorek miesiąca): [1] Pełny przegląd macierzy RACI i dostępów uprzywilejowanych — recertyfikacja. [2] Rotacja sekretów zgodnie z harmonogramem (klucze sesyjne, API keys, service accounts). [3] Red team exercise — minimum 1 scenariusz z katalogu ataków (sekcja powyżej). [4] Aktualizacja planów DR — test RTO/RPO. [5] Aktualizacja whitelist ASN dla komunikatorów (BGP/RIPE/ARIN). [6] Weryfikacja integralności obrazów bazowych (hash comparison vs baseline registry). [7] Przegląd logów retencji i polityk WORM — weryfikacja nienaruszalności.

104.4 Monthly ops checklist

Co miesiąc (pierwszy tydzień miesiąca) przeprowadzany jest pełny przegląd operacyjny:

Access recertification: - [] Przegląd wszystkich kont administracyjnych: czy każde konto jest nadal potrzebne? - [] Weryfikacja uprawnień: czy principle of least privilege jest zachowane? - [] Przegląd service accounts: czy credentials nie wygasły? - [] Usunięcie/dezaktywacja kont nieaktywnych (>60 dni bez logowania)

Backup restore test: - [] Wykonanie restore testu z losowego backupu (minimum 1 komponent/miesiąc) - [] Weryfikacja integralności przywróconych danych (hash comparison) - [] Pomiar czasu restore vs RTO target - [] Dokumentacja wyników

Compliance metrics review: - [] Przegląd metryk compliance: uptime SLA, incident response times, audit findings open - [] Sprawdzenie: czy wszystkie action items z audytów są na track? - [] Weryfikacja zgodności retencji danych z polityką

SLA report generation: - [] Wygenerowanie raportu SLA per klient: uptime, response times, incidents - [] Porównanie z contractual SLA targets - [] Jeśli SLA breach: inicjacja procedury remediation i customer communication

Wynik: Monthly ops report prezentowany na monthly ops review meeting. Eskalacje do CTO jeśli: access recertification wykazuje problemy, restore test failed, SLA breach.

104.5 Upgrade guides

Każdy komponent SYLION ma dedykowaną procedurę aktualizacji. Upgrade guides muszą być aktualizowane przy każdym release i testowane w staging przed zastosowaniem w produkcji.

Struktura per-component upgrade guide: 1. Pre-upgrade checklist: - Weryfikacja kompatybilności (release notes, dependency matrix) - Backup aktualnego stanu (snapshot) - Komunikacja do dotkniętych operatorów (maintenance window notification) - Weryfikacja, że rollback procedure jest aktualna

Upgrade procedure:

Krok-po-kroku instrukcja (ponumerowane kroki)

Expected output na każdym kroku

Timeout per krok (jeśli krok trwa dłużej → abort)

Dual authorization wymagane dla upgrade komponentów krytycznych (G1, G2, HSM)

Post-upgrade verification:

Health check per komponent

Functional test (end-to-end session, policy evaluation, CDR processing)

Performance test (latency, throughput comparison before/after)

Monitoring: wzmocniony monitoring 24h po upgrade

Rollback procedure:

Krok-po-kroku instrukcja rollback

Trigger rollback: jakie warunki uzasadniają rollback? (failed health check, performance degradation >20%, security regression)

Rollback testing requirements (co najmniej raz w staging per release)

Testing requirements: - Każdy upgrade musi być najpierw wykonany w staging environment - Staging musi odzwierciedlać produkcję (same components, same configuration, representative load) - Upgrade w staging: full test suite + smoke test + performance test - Sign-off: Ops Lead + Security Engineer before production deployment

104.6 DR guides

Procedury Disaster Recovery są krytyczne dla ciągłości działania SYLION. DR guides muszą być testowane kwartalnie (Rozdział 104.3) i aktualizowane po każdym teście.

Step-by-step regional failover: 1. Detekcja: Monitoring potwierdza niedostępność primary region (≥ 2 niezależne źródła, nie single point of failure w monitoringu) 2. Decyzja: IC lub Ops Lead autoryzuje failover (dual auth jeśli poza maintenance window) 3. DNS/routing update: Przekierowanie ruchu do secondary region (TTL DNS: niski, pre-configured) 4. Service verification: Health check wszystkich komponentów w secondary region 5. Data verification: Sprawdzenie replication lag — jak aktualne są dane w secondary? 6. Operator notification: Komunikacja do operatorów o failover (automatyczny banner w sesji) 7. Monitoring: Wzmocniony monitoring secondary region

Full recovery procedure (failback to primary): 1. Primary region restored: Potwierdzenie, że infrastruktura primary jest zdrowa 2. Data reconciliation: Synchronizacja danych z secondary → primary (replication catch-up) 3. Verification: Full test suite w primary region 4. Gradual failback: Stopniowe przekierowanie ruchu (10% → 50% → 100%) 5. Monitoring: Wzmocniony monitoring 48h po failback 6. Deactivation: Dezaktywacja trybu DR, przywrócenie normalnych procedur

RTO/RPO targets: - RTO (Recovery Time Objective): <30 minut dla failover, <4 godziny dla full recovery - RPO (Recovery Point Objective): <5 minut (synchronous replication) dla danych krytycznych, <1 godzina dla danych operacyjnych

104.7 Break-glass guides

Procedura break-glass umożliwia awaryjny dostęp do systemu w sytuacjach, gdy normalne mechanizmy uwierzytelniania/autoryzacji nie działają. Jest to procedura ostateczna — używana wyłącznie gdy inne metody zawiodły.

Kiedy używać break-glass: - Obaj autoryzowani administratorzy niedostępni, a system wymaga natychmiastowej interwencji - Awaria systemu IAM uniemożliwiająca normalne logowanie - Incydent P1 wymagający działań, których normalny flow autoryzacji uniemożliwia (np. IAM jest częścią incydu)

Procedura autoryzacji: 1. Administrator requesting break-glass kontaktuje się z CISO (lub Deputy CISO) 2. CISO weryfikuje uzasadnienie i autoryzuje break-glass (telefonicznie + email confirmation) 3. Administrator używa sealed break-glass credentials (przechowywanych w fizycznym sejfie, dual access) 4. Każde użycie break-glass credentials jest natychmiast logowane w Zone 4 (tamper-proof)

Działania podczas break-glass: - Dozwolone: tylko działania niezbędne do rozwiązania bezpośredniego problemu - Niedozwolone: jakiegokolwiek działania wykraczające poza zakres uzasadnienia - Wszystkie operacje są logowane z flagą break-glass=true - Czas trwania break-glass session: maksymalnie 4 godziny. Przedłużenie wymaga ponownej autoryzacji CISO

Cleanup po break-glass: 1. Natychmiastowa rotacja break-glass credentials (nowe credentials do sejfu) 2. Przegląd wszystkich operacji wykonanych podczas break-glass (audit review przez CISO) 3. Obowiązkowy incident report (nawet jeśli break-glass nie był częścią formalnego incydu) 4. Assessment: czy normalne mechanizmy mogły być użyte? Jeśli nie — dlaczego? (feed-back loop do architektury) 5. Nowe break-glass credentials sealed i umieszczone w sejfie (dual custody)

Audyt break-glass: Każde użycie break-glass jest automatycznie raportowane na monthly security review. CISO prezentuje: liczbę użyć, uzasadnienia, review wyników. Target: 0 użyć break-glass w normalnych warunkach operacyjnych.

104.8 Offboarding admina

Offboarding administratora jest procesem security-critical. Opóźnienie lub niekompletny offboarding stanowi poważne ryzyko (orphaned privileged access).

Natychmiastowe (dzień 0 — dzień decyzji o offboardingu): 1. Dezaktywacja konta administracyjnego w IAM (nie usunięcie — zachowanie audit trail) 2. Unieważnienie FIDO2 tokena 3. Unieważnienie certyfikatów powiązanych z adminem 4. Revoke access do repozytoriów kodu, dokumentacji, systemów zarządzania 5. Revoke access do crisis room i kanałów incyduwowych 6. Revoke VPN/remote access

Rotacja credentials (dzień 0–1): - Rotacja shared secrets, do których admin miał dostęp - Jeśli admin znał break-glass credentials: natychmiastowa rotacja i re-sealing - Rotacja API keys/tokens, które admin mógł znać - Zmiana kodów dostępu do fizycznych lokalizacji (data center, server room)

Knowledge transfer (przed offboardowaniem, jeśli planowy): - Przekazanie ownership runbooków, playbooków - Dokumentacja nieformalnej wiedzy (tribal knowledge) - Przekazanie access credentials do systemów, których admin był jedynym operatorem (single point of failure — audit finding jeśli takie istnieją)

Audyt post-offboarding (dzień 7): - Weryfikacja, że wszystkie dostępy zostały odwołane (comprehensive access audit) - Sprawdzenie: czy admin miał access do systemów nieuwzględnionych w IAM (shadow IT)? - Review: czy offboarding ujawnił single points of failure? - Dokumentacja w HR z retencją 2 lata

SLA offboardingowe: - Planowy offboarding: access revocation w dniu odejścia, credential rotation w ciągu 24h - Natychmiastowy offboarding (termination): access revocation w ciągu 1 godziny od decyzji

CZĘŚĆ XIII — DOKUMENTACJA, SZKOLENIA I ADOPCJA

Rozdział 105. Szkolenia i programy certyfikacyjne

Status: [N] Normatywny Odbiorca: Training Lead, HR, SOC, Engineering, Partnerzy Wpływ na baseline: Wysoki Powiązane rozdziały: 99, 102, 104, 106

105.1 Program operatora

Program szkoleniowy operatora przygotowuje użytkownika końcowego do bezpiecznego i efektywnego korzystania z platformy SYLION. Operator to osoba korzystająca z terminala — prawnik, dziennikarz, polityk, executive — często bez głębokiej wiedzy technicznej. Szkolenie musi być przystępne, praktyczne i skoncentrowane na scenariuszach.

Zakres szkolenia:

Konfiguracja terminala (60 min):

Unboxing i pierwsze uruchomienie terminala SYLION

Enrollment FIDO2 token (hands-on z urządzeniem fizycznym)

Konfiguracja routera SYLION (podłączenie, first boot, weryfikacja połączenia)

Test end-to-end: nawiązanie pierwszej sesji

Nawiązywanie sesji (45 min):

Logowanie do platformy (FIDO2 + PIN)

Nawiązywanie sesji desktopowej

Rozłączanie i ponowne łączenie

Co się dzieje gdy sesja wygasa (timeout, reconnect)

Zachowanie terminala przy utracie łączności

Transfer plików przez CDR (45 min):

Jak wysłać plik (staging zone, CDR processing)

Jakie typy plików są akceptowane/odrzucone (policy-driven)

Dlaczego plik może zostać odrzucony (CDR dezynfekcja)

Potwierdzenie dostarczenia

Ograniczenia transferów (rozmiar, wolumen)

Komunikacja głosowa i video (30 min):

Nawiązywanie połączenia głosowego

Połączenia konferencyjne

Jakość audio — co robić przy problemach

Matrix messaging — podstawy

Procedura utraty urządzenia (30 min):

Krytyczne: Jak zgłosić utratę terminala (numer hotline SOC, email, procedura)

Co się dzieje po zgłoszeniu (sesja unieważniona, credentials zablokowane)

Procedura re-enrollment (sealed recovery key, dual auth, 15-minutowe okno)

Terminal nie przechowuje danych — wyjaśnienie, dlaczego utrata terminala nie oznacza wycieku danych

Duress response (30 min):

Co to jest tryb wymuszenia (duress mode)

Jak aktywować duress response (dedykowany PIN/FIDO2 gesture)

Co się dzieje po aktywacji (sesja wygląda normalnie, ale powiadamia SOC)

Kiedy używać: przymus fizyczny, szantaż, przeszukanie pod przymusem

Scenariusze praktyczne (symulacja)

Czas trwania: 4 godziny (szkolenie wstępne). Forma: stacjonarne lub remote z instruktorem.

Annual refresh: 2 godziny — aktualizacja procedur, nowe funkcje, powtórzenie krytycznych scenariuszy (utrata urządzenia, duress). Obowiązkowy — brak odświeżenia skutkuje zawieszeniem dostępu po 13 miesiącach od ostatniego szkolenia.

Weryfikacja: Krótki test wiedzy (10 pytań, minimum 70% poprawnych) na zakończenie szkolenia. Wynik rejestrowany w systemie szkoleniowym.

105.2 Program admina

Program szkoleniowy administratora jest znacznie bardziej zaawansowany i obejmuje pełne zarządzanie platformą, incident response i operacje bezpieczeństwa.

Zakres szkolenia (2-dniowe szkolenie wstępne):

Dzień 1 — Architektura i zarządzanie (8h):

Architektura SYLION (2h):

Model Zero Trust — dlaczego i jak

Thin Client, G1/G2, session broker, workloads microVM

IPsec IKEv2, Firecracker, AMD SEV-SNP/TDX (STATE)

Matrix core, CDR pipeline, HSM/PKI

Zone 4: WORM, hash chain, BYO-KMS

IAM Management (2h):

Provisioning operatorów i adminów

FIDO2 enrollment i re-enrollment

Role i uprawnienia (RBAC)

Access recertification (procedura monthly, Rozdział 104.4)

Offboarding — procedura krok-po-kroku

Policy management (2h):

G2 policy engine — jak definiować polityki

CDR policies — file type restrictions, volume limits

Session policies — timeout, reconnect, concurrent sessions

Policy testing w staging environment

Policy deployment (dual auth required)

Monitoring i alerting (2h):

Dashboard SIEM — przegląd i interpretacja

Alert triage — co jest false positive, co wymaga akcji

Zone 4 — jak weryfikować integralność logów

Metryki operacyjne — co monitorować, jakie prognozy

Dzień 2 — Incident response i bezpieczeństwo (8h):

Incident response (3h):

Proces IR (Rozdział 98) — triage → containment → eradication → recovery

Playbooki (Rozdział 99) — przegląd kluczowych playbooków (99.1, 99.3, 99.9, 99.10, 99.15)

Symulacja: tabletop exercise z scenariuszem P2

Break-glass (1h):

Kiedy i jak użyć break-glass

Procedura autoryzacji

Cleanup po break-glass

Hands-on: symulacja break-glass w staging

Dual authorization (1h):

Jakie operacje wymagają dual auth

Procedura dual auth (request → approve → execute)

Co robić gdy second admin jest niedostępny

Audit trail dual auth

Compliance (2h):

GDPR obowiązki: data processing, breach notification, data subject rights

NIS2 obowiązki: reporting, security measures

Obowiązki dokumentacyjne: co logować, jak retencjonować

Procedura legal seizure request (playbook 99.15) — co robić, czego nie robić

Egzamin (1h):

Test wiedzy (30 pytań, minimum 80%)

Praktyczne zadanie w staging environment

Quarterly drill: Co kwartał obowiązkowe ćwiczenie symulacyjne (tabletop exercise) obejmujące losowy scenariusz incydentowy. Czas trwania: 2 godziny. Wynik: pass/fail. Failure: dodatkowe szkolenie korygujące w ciągu 30 dni.

105.3 Program SOC/IR

Program szkoleniowy dla analityków Security Operations Center i członków Incident Response Team. Skupia się na umiejętnościach detekcji, analizy i reagowania.

Zakres szkolenia (1-dniowe szkolenie wstępne, 8h):

Alert triage (2h):

Źródła alertów w SYLION: SIEM, IDS/IPS, anomaly detection, component health checks

Metodyka triage: severity assessment, false positive identification, correlation

SLA na triage: P1 (5 min), P2 (15 min), P3 (1h), P4 (4h)

Hands-on: triage 10 symulowanych alertów (mix real incidents i false positives)

Playbook execution (3h):

Przegląd wszystkich 15 playbooków (Rozdział 99)

Deep dive: 5 najczęstszych scenariuszy

Hands-on: execution playbooku 99.1 (utrata terminala) i 99.6 (kompromitacja workloadu) w staging

Decyzje: kiedy eskalować, kiedy containment wystarczy

Forensic evidence collection (2h):

Zasady dowodowe (Rozdział 100.1)

Jak zabezpieczyć dowody z Zone 4 (hash verification, extraction)

Chain of custody — dokumentacja

Granice forensic readiness — co SYLION może/nie może dostarczyć

Hands-on: zabezpieczenie dowodów z symulowanego incydentu

Escalation (1h):

Kiedy eskalować: P3→P2, P2→P1, wewnętrzna → externa (CISO, Legal, regulatora)

Jak eskalować: kanały, format, informacje wymagane

Komunikacja z IC podczas aktywnego incydentu

Dokumentacja eskalacji

Monthly simulation: Co miesiąc obowiązkowa symulacja incydentu (red team / blue team exercise lub tabletop). Scenariusze rotowane — każdy z 15 playbooków musi być przetestowany co najmniej raz w roku. Wyniki dokumentowane, metryki: time to detect, time to contain, playbook compliance.

105.4 Program partnera wdrożeniowego

Partnerzy wdrożeniowi muszą posiadać głęboką wiedzę o platformie SYLION, aby prawidłowo wdrażać ją u klientów.

Zakres szkolenia (3-dniowy kurs certyfikacyjny):

Dzień 1 — Architektura i bezpieczeństwo (8h): - Pełna architektura SYLION (wszystkie warstwy) - Model bezpieczeństwa: Zero Trust, E2EE, Confidential Computing - Tier: STANDARD, PRO, STATE — różnice, kiedy który - Compliance framework: GDPR, NIS2, certyfikacje - Security white paper — przegląd i interpretacja

Dzień 2 — Wdrożenie i operacje (8h): - Procedury wdrożenia: discovery → assessment → pilot → rollout - Provisioning środowisk klientów - Konfiguracja per-tier: STANDARD (400€/user), PRO (1500€/user), STATE (2500€/user, min 50) - Onboarding operatorów — jak przeprowadzić szkolenie - Troubleshooting: najczęstsze problemy wdrożeniowe - Integration guides — jak integrować z istniejącą infrastrukturą klienta

Dzień 3 — Wsparcie i certyfikacja (8h): - Model wsparcia: L1 partner → L2 partner → L3 SYLION - Eskalacja: kiedy i jak eskalować do SYLION - Customer success: metryki adopcji, executive reporting - Hands-on: pełne wdrożenie w lab environment (provisioning → onboarding → first session) - Egzamin certyfikacyjny (40 pytań + praktyczny lab, minimum 85%)

Recertyfikacja: Coroczna (1 dzień — aktualizacja + egzamin). Brak recertyfikacji = utrata statusu certyfikowanego partnera.

105.5 Program deweloperski

Program dla deweloperów integrujących swoje systemy z SYLION API lub rozwijających rozszerzenia platformy.

Zakres szkolenia (1-dniowe szkolenie + hands-on):

API integration (3h):

Architektura API SYLION (REST, WebSocket, gRPC — per use case)

Uwierzelnianie: OAuth 2.0, mTLS, API keys — kiedy który

OpenAPI spec — jak czytać i wykorzystywać

Rate limiting, pagination, error handling

Hands-on: first API call → list operators → create session

- SDK usage (2h):
- Dostępne SDK (Python, Go, TypeScript)
- Instalacja i konfiguracja
- Najczęstsze patterns: session management, file transfer, webhook handling
- Hands-on: budowa prostej integracji (np. automated file transfer pipeline)
- Security requirements (2h):
- Wymagania bezpieczeństwa dla integracji: credential storage, TLS pinning, input validation
- Code review checklist dla integracji SYLION
- Vulnerability disclosure: jak raportować znalezione podatności
- Hands-on: security audit przykładowej integracji
- Testing (1h):
- Sandbox environment — jak konfigurować i używać
- Contract testing — weryfikacja zgodności integracji ze specyfikacją API
- Mock server — testowanie bez live API
- CI/CD integration — automatyczne testy integracyjne
- Materiały: Pełna dokumentacja API, SDK, sample code, sandbox credentials. Dostępne w developer portal po zaakceptowaniu Developer Agreement.

105.6 Egzaminy i certyfikacja wewnętrzna

System certyfikacji wewnętrznej zapewnia, że osoby wykonujące role krytyczne posiadają potwierdzone kompetencje.

Poziomy certyfikacji:

Poziom	Rola	Egzamin	Próg zaliczenia	Ważność
Operator Certified	Operator	10 pytań (test)	70%	1 rok
Admin Certified	Administrator	30 pytań + lab	80%	1 rok
SOC/IR Certified L1	Analitik SOC junior	20 pytań + triage sim	75%	1 rok
SOC/IR Certified L2	Analitik SOC senior / IR	30 pytań + incident sim	85%	1 rok
SOC/IR Certified L3	IR Lead / Incident Commander	40 pytań + full exercise	90%	1 rok
Partner Certified	Partner wdrożeniowy	40 pytań + lab	85%	1 rok
Developer Certified	Deweloper integrator	25 pytań + code review	80%	1 rok

Format egzaminu: - Pytania wielokrotnego wyboru i pytania otwarte (scenariuszowe) - Część praktyczna: lab exercise w staging environment (dla Admin, SOC/IR, Partner) - Czas: 60–120 minut zależnie od poziomu - Egzamin przeprowadzany zdalnie (proctored) lub stacjonarnie

Passing criteria: - Minimum % poprawnych odpowiedzi (per poziom, tabela powyżej) - Dla części praktycznej: ukończenie zadania w wymaganym czasie z poprawnym wynikiem - Brak „krytycznych failures” — niektóre pytania/zadania są oznaczone jako critical (np. „czy użyłeś dual auth do zmiany polityk?”) — failure na critical = failure całego egzaminu niezależnie od wyniku ogólnego

Renewal cadence: Wszystkie certyfikacje ważne są 1 rok. Odnowienie: egzamin renewal (skrócony — 50% zakresu full exam) lub udział w odpowiedniej liczbie drills/simulations w ciągu roku (minimum 4 dla SOC/IR, 2 dla Admin).

105.7 Ścieżki kompetencyjne

Ścieżki kompetencyjne definiują rekomendowaną kolejność szkoleń i certyfikacji dla poszczególnych ról. Pomagają w planowaniu rozwoju zawodowego i zapewniają, że osoby awansujące na bardziej odpowiedzialne role posiadają niezbędne fundamenty.

Ścieżka Operatora:

Operator Certified (basic) → Annual Refresh → [opcjonalnie] Power User Training

Ścieżka minimalna — wystarczająca dla większości operatorów.

Ścieżka Administratora:

Operator Certified → Admin Training Day 1 → Admin Training Day 2 → Admin Certified → Quarterly Drills → Annual Recertification → [opcjonalnie] SOC/IR Certified L1 (cross-training)

Prerequisites: Operator Certified. Zalecane: 6 miesięcy doświadczenia z platformą SYLION jako operator.

Ścieżka SOC/IR:

SOC/IR Certified L1 → Monthly Simulations → SOC/IR Certified L2 (po 6 miesiącach) → Monthly Simulations + Incident Experience → SOC/IR Certified L3 (po 12 miesiącach) → Incident Commander Training

Prerequisites: Admin Certified (lub równoważna wiedza). Zalecane: doświadczenie z 2+ real incidents przed L3.

Ścieżka Partnera:

Partner Training Day 1-3 → Partner Certified → Annual Recertification → [opcjonalnie] SOC/IR Certified L1 (enhanced support capability) → [opcjonalnie] Developer Certified (integration projects)

Prerequisites: brak formalnych (wiedza IT networking i security na poziomie CISSP/CCNA recommended).

Ścieżka Dewelopera:

Developer Training → Developer Certified → Annual Recertification → [opcjonalnie] Security Advanced Training

Prerequisites: doświadczenie z API REST, znajomość jednego z języków SDK (Python/Go/TypeScript).

Rozdział 106. FAQ, troubleshooting i baza wiedzy

Status: [R] Rekomendowany Odbiorca: Operatorzy, Administratorzy, Integratorzy, SOC, Support Wpływ na baseline: Średni Powiązane rozdziały: 104, 105, 107

106.1 FAQ operatora

Poniżej lista najczęściej zadawanych pytań operatorów z odpowiedziami. Lista ta musi być utrzymywana przez Support Team i aktualizowana co kwartał na podstawie statystyk ticketów.

Q1: Dlaczego moja sesja wygasła? Sesja SYLION ma skonfigurowany timeout (domyślnie 15 minut braku aktywności, konfigurowalny przez administratora). Po wygaśnięciu musisz ponownie nawiązać sesję za pomocą FIDO2 tokena. Terminal nie przechowuje stanu sesji — jest to zamierzona cecha bezpieczeństwa.

Q2: Co zrobić przy utracie klucza FIDO2? Natychmiast skontaktuj się z SOC hotline (numer otrzymany podczas onboarding). SOC zablokuje Twój stary token. Następnie potrzebna jest procedura re-enrollment z użyciem sealed recovery key — wymaga dual authorization od dwóch administratorów i 15-minutowego okna czasowego. Nowy FIDO2 token zostanie wydany.

Q3: Dlaczego plik jest odrzucany przez CDR? System CDR (Content Disarm and Reconstruction) analizuje każdy przesyłany plik. Plik może zostać odrzucony z powodów: (a) typ pliku zabroniony przez politykę (np. .exe, .bat), (b) plik zawiera aktywną zawartość, której CDR nie może bezpiecznie zdezynfekować, (c) plik przekracza limit rozmiaru, (d) plik nie przeszedł skanowania antymalware. Skontaktuj się z administratorem, aby dowiedzieć się, który warunek spowodował odrzucenie.

Q4: Jak działa tryb wymuszenia (duress)? Tryb duress aktywujesz dedykowanym PINem lub gestem FIDO2 (otrzymanym podczas szkolenia). Po aktywacji sesja wygląda normalnie, ale system powiadamia SOC o sytuacji przymusu. SOC podejmuje odpowiednie działania zgodnie z playbook. Nigdy nie informuj osoby wymuszającej o istnieniu trybu duress.

Q5: Czy moje dane są bezpieczne po kradzieży terminala? Tak. Terminal SYLION jest thin klientem — nie przechowuje żadnych danych, plików, kluczy sesji ani historii komunikacji. Kradzież terminala nie daje atakującemu dostępu do Twoich danych. Po zgłoszeniu kradzieży SOC natychmiast blokuje terminal.

Q6: Dlaczego nie mogę kopiować tekstu z sesji do zewnętrznego programu? SYLION celowo blokuje schowek między sesją a systemem lokalnym. Jest to ochrona przed exfiltracją danych. Jeśli potrzebujesz przenieść dane, użyj autoryzowanego kanału transferu (CDR).

Q7: Co się stanie, gdy utracę łączność w trakcie sesji? Sesja zostanie zawieszona. Po przywróceniu łączności możesz wznowić sesję (jeśli nie wygasła timeout). Jeśli sesja wygasła — nawiąż nową. Twoja praca w workloadzie jest zachowana (microVM nie jest niszczone przy rozłączeniu).

Q8: Jak zmienić PIN do FIDO2? Zmianę PIN przeprowadzasz samodzielnie na swoim FIDO2 tokenie. Jeśli zapomnisz PIN — skontaktuj się z SOC dla procedury re-enrollment (analogicznie do utraty tokena).

Q9: Czy administrator może czytać moje wiadomości? Nie. Komunikacja Matrix jest szyfrowana end-to-end (E2EE). Klucze szyfrujące są na Twoim urządzeniu. Administrator widzi metadane (kto z kim, kiedy), ale nie treść wiadomości.

Q10: Czy mogę używać SYLION na własnym komputerze? Nie. SYLION wymaga dedykowanego terminala thin client. Instalacja oprogramowania na własnym urządzeniu nie jest wspierana. Terminal zapewnia czysty, kontrolowany system operacyjny bez możliwości lokalnej kompromitacji.

Q11: Dlaczego połączenie głosowe jest opóźnione? Połączenia przechodzą przez szyfrowane tunele IPsec i sieć SYLION. Pewne opóźnienie (latency) jest normalne. Jeśli opóźnienie przekracza 200ms lub jakość jest niska — sprawdź połączenie routera SYLION, upewnij się, że nie korzystasz z publicznego Wi-Fi o niskiej przepustowości, i zgłoś problem administratorowi.

Q12: Jak wygląda aktualizacja terminala? Aktualizacje terminala są automatyczne — terminal pobiera aktualizację przy kolejnym uruchomieniu. Nie musisz nic robić. Administrator planuje maintenance window i powiadomi Cię jeśli aktualizacja wymaga restartu.

Q13: Co to jest kill switch routera? Kill switch to mechanizm awaryjnego wyłączenia routera SYLION. W razie kompromitacji lub kradzieży routera, SOC może zdalnie wyczyścić jego konfigurację, uniemożliwiając odczytanie kluczy VPN.

Q14: Czy mogę korzystać z SYLION za granicą? Tak, SYLION działa z dowolnej lokalizacji z dostępem do internetu. Router SYLION zapewnia szyfrowane połączenie niezależnie od lokalnej sieci. Pamiętaj o przepisach lokalnych dotyczących szyfrowania — w niektórych krajach użycie VPN może być ograniczone.

Q15: Dlaczego muszę potwierdzać urządzenie w Matrix? Weryfikacja urządzenia (device verification) to element E2EE. Potwierdza, że rozmawiasz z prawdziwym urządzeniem drugiej osoby, nie z atakującym. Jest to ochrona przed man-in-the-middle.

Q16: Co zrobić, gdy widzę nieznaną osobę w sesji Matrix? Natychmiast zgłoś to administratorowi lub SOC hotline. Nie weryfikuj nieznanego urządzenia. Może to być próba przechwycenia komunikacji. SOC zbada sprawę.

Q17: Jak często powinienem zmieniać hasło/PIN? SYLION używa FIDO2 (hardware key), nie haseł. PIN do FIDO2 powinien być zmieniany co 6 miesięcy lub natychmiast jeśli podejrzewasz, że ktoś go poznał.

Q18: Czy SYLION nagrywa moje rozmowy? Nie. Rozmowy głosowe i video są szyfrowane E2EE i nie są nagrywane przez platformę. SYLION przechowuje jedynie metadane (czas połączenia, uczestnicy, czas trwania).

Q19: Co się stanie z moimi danymi po zakończeniu współpracy z SYLION? Twój workload (microVM) zostanie zniszczony. Dane w Zone 4 (logi, metadane) podlegają polityce retencji. Treść komunikacji E2EE jest nieodtwarzalna bez kluczy urządzeń.

Q20: Kogo kontaktować w razie problemów? Pierwszy kontakt: administrator Twojej organizacji. W sytuacjach krytycznych (utrata urządzenia, przymus, podejrzenie kompromitacji): SOC hotline (numer 24/7 otrzymany podczas onboardingu).

106.2 FAQ administratora

Q1: Jak zprovisionować nowego operatora? Przez management console: IAM → Operators → New. Wymagane: imię, email, rola, przypisanie do klienta/organizacji. System wygeneruje invitation token. Operator musi dokonać enrollment FIDO2 w ciągu 7 dni (konfigurowalny).

Q2: Co zrobić, gdy dual auth partner jest niedostępny? Jeśli żaden z autoryzowanych adminów dual auth nie jest dostępny w ciągu SLA (P1: 15 min, P2: 1h): eskalacja do CISO. Jeśli CISO potwierdzi krytyczność: procedura break-glass (Rozdział 104.7). NIE próbuj obejść dual auth.

Q3: Certyfikat komponentu wygasa za 7 dni — co zrobić? Zainicjuj procedurę renewal: Management Console → Certificates → Renew. Renewal wymaga dual auth. Po renewal: test connectivity komponentu. Certyfikaty powinny być renewal'owane 30 dni przed wygaśnięciem (alert w daily ops checklist).

Q4: Jak rozwiązać konflikt polityk w G2? Konflikty polityk (dwie polityki z sprzecznymi decyzjami) są rozwiązywane przez G2 na zasadzie: deny wins (jeśli jedna polityka deny, wynik deny). Aby zdiagnozować: Management Console → Policies → Simulate → wpisz scenariusz → zobacz evaluation trace. Zmiana polityk wymaga dual auth.

Q5: Operator zgłasza brak dostępu — jak zdiagnozować? Checklist: (1) Czy konto operatora jest aktywne w IAM? (2) Czy FIDO2 token jest ważny? (3) Czy terminal jest zarejestrowany? (4) Czy polityki G2 nie blokują dostępu? (5) Czy sesja nie jest zamrożona (incydent)? → Management Console → Operators → [operator] → Diagnostic.

Q6: Kiedy mogę użyć break-glass? Wyłącznie gdy: (a) normalne mechanizmy uwierzytelniania nie działają I (b) system wymaga natychmiastowej interwencji I (c) autoryzacja CISO została uzyskana. Break-glass NIE jest skrótem dla niecierpliwości.

Q7: Jak przeprowadzić offboarding operatora? Management Console → Operators → [operator] → Deactivate. System automatycznie: unieważnia sesję, blokuje FIDO2, niszczy workload microVM. Credentials nie wymagają manualnej rotacji (per-operator isolation).

Q8: Backup restore test nie przeszedł — co dalej? (1) Zidentyfikuj przyczynę failure (log → error code). (2) Jeśli data corruption: sprawdź integralność backupu (hash verification). (3) Jeśli procedura fault: popraw runbook. (4) Ponów test. (5) Jeśli powtarzalny failure: eskalacja do Ops Manager + playbook 99.12.

106.3 FAQ integratora

Q1: Jak uwierzytelnić się do API SYLION? SYLION API wspiera trzy metody uwierzytelniania: (a) OAuth 2.0 client credentials flow — dla server-to-server integracji, (b) mTLS — dla integracji wymagających najwyższego poziomu bezpieczeństwa, (c) API key — dla integracji deweloperskich (sandbox only, nie dla produkcji). Szczegóły: Rozdział 103.4 i integration guide.

Q2: Jak skonfigurować webhook? Management Console → Integrations → Webhooks → New. Podaj URL endpointu, events do subskrypcji, secret do HMAC verification. SYLION podpisuje każdy webhook payload HMAC-SHA256 — Twój endpoint musi weryfikować podpis. Retry policy: 3 próby (1s, 30s, 5min), potem DLQ (dead letter queue).

Q3: SDK zwraca błąd timeout — co zrobić? Sprawdź: (1) czy endpoint API jest osiągalny (curl test), (2) czy nie przekraczasz rate limit (check response headers X-RateLimit-*), (3) czy Twój request nie jest zbyt duży (payload limits w documentation), (4) czy certyfikat TLS jest ważny (mTLS). Jeśli problem persists: włącz debug logging w SDK i wyślij trace do support.

Q4: Jak testować integrację bez live API? Użyj sandbox environment (Rozdział 103.4) lub mock servera generowanego z OpenAPI spec. Sandbox credentials: developer portal → API Keys → Sandbox. Rate limits w sandbox są niższe niż produkcyjne.

Q5: Jak obsłużyć deprecation API endpoint? Monitoruj header Deprecation: true w response. Kiedy pojawia się ten header: zaplanuj migrację do nowego endpointu (opisanego w response header Link: <new-url>; rel="successor-version"). Deprecation period: minimum 12 miesięcy dla major changes.

106.4 Troubleshooting sesji

Problem: Wysokie opóźnienie sesji (latency > 200ms)

Diagnoza krok-po-kroku: 1. Sprawdź latency routera SYLION: Management Console → Routers → [router] → Diagnostics → Ping test 2. Sprawdź latency na ścieżce Terminal → G1: session diagnostic → hop-by-hop latency 3. Sprawdź obciążenie G1: dashboard → G1 metrics → CPU/RAM/network utilization 4. Sprawdź obciążenie workloadu: dashboard → Workload metrics → CPU/RAM 5. Jeśli latency na odcinku ISP→router: problem po stronie ISP operatora 6. Jeśli latency na odcinku G1→workload: sprawdź network congestion w datacenter

Problem: Sesja rozłącza się losowo (session drops)

Diagnoza: 1. Logi sesji: Zone 4 → Session logs → szukaj session_terminated z reason code 2. Reason codes: timeout (brak aktywności), policy_deny (zmiana polityki G2 w trakcie sesji), network_loss (utrata łączności), admin_revoke (admin zakończył sesję), workload_crash (microVM awaria) 3. Jeśli network_loss: sprawdź router diagnostics, ISP stability 4. Jeśli workload_crash: sprawdź workload logs, eskaluj jeśli powtarzalne

Problem: Sesja nie nawiązuje się (connection failure)

Diagnoza: 1. Sprawdź status operatora w IAM (aktywny? FIDO2 ważny?) 2. Sprawdź terminala (zarejestrowany? certyfikat ważny?) 3. Sprawdź polityki G2 (simulation: czy allow?) 4. Sprawdź session broker (health check) 5. Sprawdź workload provisioning (czy microVM jest ready?) 6. Jeśli error code AUTH_FAILED: problem z FIDO2 (re-enrollment?) 7. Jeśli error code POLICY_DENIED: sprawdź policy evaluation trace

106.5 Troubleshooting voice

Checklist jakości połączeń głosowych:

Jitter > 30ms: Sprawdź router SYLION (QoS configuration), ISP stability, obciążenie sieci lokalnej operatora

Latency > 200ms: Sprawdź routing path (hop-by-hop), obciążenie G1, region workloadu (czy zbyt daleki geograficznie?)

Packet loss > 1%: Sprawdź router diagnostics, ISP packet loss test, czy Wi-Fi operatora nie jest przeciążone

Echo: Problem po stronie endpoint audio (mikrofon operatora) — nie po stronie platformy. Rekomendacja: headset z echo cancellation

One-way audio: Sprawdź NAT traversal (router), firewall rules, IPsec SA establishment (czy oba kierunki są ustanowione?)

Codec negotiation issues: SYLION używa Opus codec (primary) z fallback na G.711. Jeśli negotiation fails: sprawdź czy oba endpointy wspierają Opus. Log: Zone 4 → Voice session logs → codec negotiation trace.

106.6 Troubleshooting routera

Problem: Kill switch nie aktywuje się 1. Sprawdź: czy router jest online? (Management Console → Routers → status) 2. Jeśli offline: kill switch wymaga łączności — konfiguracja jest zaszyfrowana kluczem sprzętowym, ale nie można jej zdalnie wyczyścić 3. Jeśli online ale kill switch nie zadziałał: sprawdź management channel (router → SYLION management plane connectivity) 4. Eskalacja: jeśli kill switch nie działa na online router → potencjalny firmware issue → playbook 99.2

Problem: DNS leak test wskazuje wyciek 1. Sprawdź konfigurację routera: czy DNS routing jest ustawiony na SYLION DNS (nie ISP DNS)? 2. Sprawdź: czy split tunnel jest wyłączony (powinien być zakazany) 3. Reconfigure router: Management Console → Routers → [router] → DNS → Force SYLION DNS 4. Retest: DNS leak test tool

Problem: Config corruption — router nie uruchamia się poprawnie 1. Nie próbuj naprawiać konfiguracji ręcznie 2. Management Console → Routers → [router] → Factory Reset 3. Re-provisioning: wygeneruj nową konfigurację → flash na router 4. Test: end-to-end connectivity test

106.7 Troubleshooting G1/G2

Problem: IPsec SA establishment failure (G1) 1. Sprawdź certyfikaty: czy certyfikat G1 jest ważny? (Management Console → Certificates) 2. Sprawdź certyfikat peer'a: czy certyfikat terminala/routera jest ważny? 3. Sprawdź IKEv2 logs: Zone 4 → IKEv2 → szukaj error code 4. Common errors: CERT_EXPIRED (renewal needed), CIPHER_MISMATCH (cipher suite negotiation failure), AUTH_FAILED (certificate not trusted) 5. Jeśli CIPHER_MISMATCH: sprawdź czy obie strony mają tę samą wersję konfiguracji cipher suite

Problem: G2 policy evaluation error 1. Sprawdź policy syntax: Management Console → Policies → Validate 2. Sprawdź policy dependencies: czy referencyjne polityki istnieją? 3. Simulation: Management Console → Policies → Simulate → wpisz scenariusz 4. Logi: Zone 4 → Policy decisions → szukaj evaluation trace z error

Problem: Routing issues (G1) 1. Sprawdź routing table G1: Management Console → G1 → Routing 2. Porównaj z expected routing (golden config) 3. Jeśli routing table jest incorrect: sprawdź czy nie było nieautoryzowanych zmian (playbook 99.3) 4. Refresh routing: Management Console → G1 → Routing → Sync from config

106.8 Troubleshooting provisioning

Problem: Environment creation failure 1. Sprawdź Firecracker: czy hypervisor ma wystarczające zasoby? (CPU, RAM, storage) 2. Sprawdź image registry: czy golden image jest dostępny i integrity-valid? 3. Sprawdź network provisioning: czy VLAN/subnet jest przypisany i dostępny? 4. Logi: provisioning pipeline logs → error code 5. Common errors: RESOURCE_EXHAUSTED (scale up), IMAGE_INTEGRITY_FAIL (re-pull image), NETWORK_CONFLICT (IP conflict, resolve in IPAM)

Problem: IAM provisioning error 1. Sprawdź: czy operator/admin nie istnieje już w systemie (duplicate check) 2. Sprawdź: czy email jest poprawny i unikalny 3. Sprawdź: czy przypisywana rola istnieje i jest aktywna 4. Logi: IAM provisioning logs → error code 5. Common errors: DUPLICATE_USER, INVALID_ROLE, QUOTA_EXCEEDED (license limit)

Problem: Certificate issuance failure 1. Sprawdź: czy PKI CA jest online i zdrowy? 2. Sprawdź: czy CSR (Certificate Signing Request) jest poprawny? 3. Sprawdź: czy quota certyfikatów nie jest wyczerpana? 4. Logi: PKI issuance logs → error code 5. Eskalacja: jeśli CA jest unhealthy → incydent (alerty SIEM powinny to wykryć)

106.9 Decision trees

Wizualne drzewa decyzyjne dla najczęstszych problemów. Muszą być dostępne w documentation portal i wydrukowane w SOC (poster format).

Decision tree 1: Sesja nie nawiązuje się

Sesja nie nawiązuje się | — Czy operator istnieje w IAM? | — NIE → Provisioning operatora (104.1) | — TAK → Czy FIDO2 token jest ważny? | — NIE → Re-enrollment FIDO2 (FAQ 106.1 Q2) | — TAK → Czy terminal jest zarejestrowany? | — NIE → Rejestracja terminala | — TAK → Czy policy G2 allows? | — NIE → Sprawdź policy trace (106.7) | — TAK → Czy session broker healthy? | — NIE → Sprawdź session broker (eskalacja) | — TAK → Czy workload provisioned? | — NIE → Provisioning workloadu (106.8) | — TAK → Eskalacja do L3

Decision tree 2: Plik odrzucony przez CDR

Plik odrzucony przez CDR | — Sprawdź CDR rejection reason code | — FILE_TYPE_BLOCKED → Zmień typ pliku lub poproś admina o wyjątek polityki | — ACTIVE_CONTENT → CDR usunął aktywną zawartość; plik dostarczony? | — TAK (sanitized) → OK, plik bezpieczny | — NIE (reject) → Plik nie może być bezpiecznie zdezynfekowany; użyj innego formatu | — SIZE_EXCEEDED → Zmniejsz rozmiar pliku lub poproś admina o zwiększenie limitu | — MALWARE_DETECTED → Plik zainfekowany; NIGDY nie próbuj obejść CDR | — UNKNOWN → Eskalacja do L2 support

Decision tree 3: MFA (FIDO2) failure

FIDO2 authentication failure | — Czy token fizycznie działa (LED miga)? | — NIE → Wymień token (uszkodzony hardware) | — TAK → Czy PIN poprawny? | — NIE → Spróbuj ponownie; po 8 błędnych PIN → token zablokowany → re-enrollment | — TAK → Czy terminal rozpoznaje token? | — NIE → Sprawdź port USB / NFC; restart terminala | — TAK → Czy error code w logach? | — AUTH_EXPIRED → Token certificate expired → re-enrollment | — TOKEN_REVOKED → Token zablokowany (po incydencie?) → kontakt SOC | — UNKNOWN → Eskalacja do L2 support

Drzewa decyzyjne muszą być aktualizowane po każdym incydencie, który ujawnił nowy scenariusz. Training Lead zapewnia, że aktualizacje decision trees są uwzględniane w materiałach szkoleniowych.

Rozdział 107. Plan adopcji klienta i enablement

Status: [R] Rekomendowany Odbiorca: Account Management, Customer Success, Sales Engineering, Partnerzy wdrożeniowi Wpływ na baseline: Średni Powiązane rozdziały: 105, 106, 108

107.1 Discovery

Faza discovery jest pierwszym etapem zaangażowania nowego klienta i służy zrozumieniu jego potrzeb, profilu ryzyka i gotowości infrastrukturalnej. Discovery powinien być przeprowadzony przez Sales Engineer we współpracy z Account Managerem.

Needs assessment: Wywiad z klientem powinien obejmować następujące obszary: - Profil organizacji: branża, wielkość, struktura (centrala, oddziały, praca zdalna) - Profil ryzyka: jakim zagrożeniom klient jest narażony? (wywiad, surveillance, insider threat, foreign intelligence, cybercrime) - Obecne narzędzia: z czego klient korzysta obecnie? (email, komunikatory, VPN, VDI, file sharing) - Wymagania regulacyjne: GDPR, NIS2, tajemnica adwokacka, ochrona źródeł dziennikarskich, tajemnica państwowa - Wymagania operacyjne: liczba operatorów, lokalizacje, godziny operacyjne, integracje z istniejącymi systemami - Budżet i timeline: oczekiwania finansowe, timeline wdrożenia

Risk profile evaluation: Na podstawie wywiadu, Sales Engineer klasyfikuje klienta do jednej z kategorii ryzyka: - Extreme risk: dziennikarze w państwach autorytarnych, opozycja polityczna, dysydenci — wymaga tier STATE, dedicated infrastructure - High risk: kancelarie prawne (tajemnica adwokacka), executive protection, organizacje pozarządowe — wymaga minimum tier PRO - Standard risk: korporacje (IP protection), organizacje z podwyższonymi wymaganiami — tier STANDARD lub PRO - Klasyfikacja ryzyka determinuje rekomendację tier i konfigurację zabezpieczeń

Tier recommendation: Na podstawie profilu ryzyka, liczby operatorów i wymagań: - STANDARD (400€/user): organizacje z podwyższonymi wymaganiami bezpieczeństwa, brak wymogów confidential computing - PRO (1500€/user): organizacje z wymaganiami compliance (GDPR, tajemnica zawodowa), potrzebujące zaawansowanego CDR, enhanced monitoring - STATE (2500€/user, min 50 operatorów): organizacje rządowe, najwyższe wymagania (AMD SEV-SNP/TDX, sovereign deployment, BYO-KMS)

Infrastructure requirements check: Weryfikacja gotowości infrastrukturalnej klienta: - Łącze internetowe: minimum 10 Mbps na operatora (25 Mbps rekomendowane dla voice/video) - Fizyczne bezpieczeństwo: czy lokalizacja operatora umożliwia bezpieczne przechowywanie terminala i routera? - Zasilanie: UPS rekomendowany (zwłaszcza w lokalizacjach niestabilnych) - Dostępność administratora: czy klient ma IT staff zdolny do roli admina, czy potrzebuje managed service?

107.2 Assessment

Faza assessment następuje po discovery i polega na szczegółowej ocenie gotowości klienta do wdrożenia SYLION.

Security posture assessment: - Przegląd obecnych polityk bezpieczeństwa klienta - Ocena dojrzałości (maturity level): ad hoc → repeatable → defined → managed → optimized - Identyfikacja luk: gdzie obecne zabezpieczenia są niewystarczające? - Rekomendacje: jakie zmiany po stronie klienta są potrzebne przed wdrożeniem SYLION?

Existing tools inventory: - Lista obecnie używanych narzędzi komunikacji i pracy zdalnej - Ocena: które narzędzia SYLION zastąpi, które będą współistnieć, które wymagają integracji - Plan migracji: jak przenieść operatorów z obecnych narzędzi na SYLION (parallel running vs cut-over)

Integration requirements: - Czy klient potrzebuje integracji SYLION z istniejącymi systemami? (IAM, email, DMS, SIEM) - Ocena techniczna: jakie API, protokoły, format danych? - Czy integracja wymaga custom development? (dodatkowy koszt i timeline)

Gap analysis: Dokument podsumowujący: co klient ma vs co potrzebuje. Kolumny: requirement, current state, gap, remediation. Gap analysis jest podstawą do stworzenia planu wdrożenia i budżetu.

107.3 Pilot

Pilotaż jest obowiązkowym etapem wdrożenia. Pozwala na weryfikację techniczną, walidację procesów i zebranie feedback od operatorów w kontrolowanym środowisku.

30-day pilot plan:

Tydzień 1 — Setup: - Provisioning środowiska pilotowego (dedicated lub shared, zależnie od tier) - Konfiguracja polityk per klient - Dostarczenie terminali i routerów do pilot operators - Szkolenie pilot operators (Rozdział 105.1)

Tydzień 2-3 — Active use: - Pilotowi operatorzy korzystają z SYLION w codziennej pracy - Równoległe korzystanie z dotychczasowych narzędzi (parallel running) - Zbieranie feedback (ankiety, wywiady 1:1) - Monitoring techniczny: latency, session stability, CDR throughput

Tydzień 4 — Evaluation: - Analiza feedback operatorów - Analiza metryk technicznych - Porównanie z success criteria - Decyzja: go / no-go / extend pilot

Success criteria: - ≥90% sesji nawiązanych bez problemów (first-attempt success rate) - Latency sesji <150ms (p95) - CDR processing time <30s (p95) - Operator satisfaction ≥4/5 (ankieta) - Zero incydentów P1/P2 podczas pilotu - Operatorzy opanowali podstawowe operacje bez wsparcia po tygodniu 2

Pilot operators selection (5-10 users): Wybór operatorów pilotowych powinien obejmować: - Osoby o różnym poziomie biegłości technicznej - Osoby z różnych lokalizacji (test łączności) - Osoby wykonujące reprezentatywne zadania (sesje desktop, voice, file transfer) - Co najmniej jednego „champion” — osobę entuzjastyczną, która pomoże w adopcji

Support model podczas pilotu: - Dedykowany kanał wsparcia (direct Matrix/email do SYLION engineering) - Czas reakcji na problemy pilotowe: <1 godzina (business hours) - Weekly check-in call z SYLION Customer Success

107.4 Controlled rollout

Po pozytywnym zakończeniu pilotu następuje kontrolowany rollout do pełnej populacji operatorów.

Fazy rollout:

Faza 1: 20% operatorów (tydzień 1-2): - Onboarding kolejnych operatorów (batch szkolenia) - Dostarczenie terminali i routerów - Monitoring: te same metryki co pilot - Kryteria eskalacji: jeśli success rate spada poniżej 85% → wstrzymanie rollout, diagnoza

Faza 2: 50% operatorów (tydzień 3-4): - Kolejna pula operatorów - Parallel running z dotychczasowymi narzędziami - Feedback sessions z operatorami - Weryfikacja skalowalności (czy platforma obsługuje większą liczbę concurrent sessions?)

Faza 3: 100% operatorów (tydzień 5-8): - Pełen onboarding - Cut-over z dotychczasowych narzędzi (jeśli decyzja klienta) - Post-rollout monitoring 30 dni

Parallel running: Podczas rollout rekomendowane jest równoległe korzystanie z SYLION i dotychczasowych narzędzi. Pozwala to na: - Bezpieczną migrację (fallback na stare narzędzia w razie problemów) - Porównanie jakości i użyteczności - Stopniowe przyzwyczajanie operatorów Cut-over (wyłączenie starych narzędzi) powinien nastąpić dopiero po potwierdzeniu stabilności SYLION przez minimum 2 tygodnie.

Rollback plan: Na każdej fazie rollout musi istnieć możliwość rollback: - Rollback fazy = przywrócenie operatorów do dotychczasowych narzędzi - Terminale SYLION: zdezaktywowane (nie zniszczone — mogą być użyte po ponowieniu rollout) - Dane: nie ma danych do migrowania back (thin client, SYLION nie zastępuje storage)

107.5 Adoption metrics

Metryki adopcji mierzą, czy operatorzy rzeczywiście korzystają z SYLION i czy platforma spełnia oczekiwania.

Key metrics:

Metryka	Definicja	Target (po 90 dniach)
Active operators/day	% operatorów z licencją, którzy nawiązali sesję danego dnia	≥80%
Session duration	Średni czas sesji (minuty)	Rośnie w trendzie
File transfers/day	Liczba transferów CDR na operatora	Zgodnie z baseline klienta
Voice calls/week	Liczba połączeń głosowych na operatora	Rośnie w trendzie
Incident rate	Liczba incydentów na 100 operatorów/miesiąc	<2
Support tickets/operator	Liczba ticketów wsparcia na operatora/miesiąc	<0.5 po 90 dniach
First-attempt session success	% sesji nawiązanych z pierwszej próby	≥95%
NPS (Net Promoter Score)	Ankieta satysfakcji operatorów	≥40

Monitoring i raportowanie: - Dashboard metrykowy: aktualizowany automatycznie, dostępny dla Account Manager i Customer Success - Weekly report: kluczowe metryki wysyłane do klienta (admin) - Monthly report: pełny raport z analizą trendów (Rozdział 107.7)

Alerty adopcji: - Operator nieaktywny >5 dni roboczych: alert do admina klienta - Active operators/day spada poniżej 70%: alert do Customer Success - Support tickets/operator wzrasta >1: analiza root cause

107.6 Change management po stronie klienta

Wdrożenie SYLION to zmiana narzędzi pracy — wymaga zarządzania zmianą (change management) po stronie organizacji klienta. SYLION powinien wspierać klienta w tym procesie.

Training plan: - Batch szkolenia operatorów (grupy 5-10 osób) prowadzone przez partnera wdrożeniowego lub SYLION trainer - Materiały szkoleniowe dostosowane do segmentu klienta (np. dla prawników: focus na tajemnicę adwokacką i ochronę dokumentów, dla dziennikarzy: focus na ochronę źródeł i duress mode) - Materiały w języku klienta (SYLION zapewnia PL, EN, DE, FR; inne na żądanie)

Champion identification: W każdej organizacji klienta powinien być zidentyfikowany co najmniej jeden champion — osoba, która: - Jest entuzjastyczna wobec nowego narzędzia - Ma autorytet wśród współpracowników - Jest dostępna jako pierwszy kontakt dla innych operatorów (peer support) - Uczestniczy w pilotażu Champion powinien otrzymać dodatkowe szkolenie (power user) i mieć bezpośredni kanał komunikacji z SYLION Customer Success.

Executive communication: Wsparcie dla klienta w komunikacji wewnętrznej: - Template komunikatu zarządu do organizacji: „Dlaczego wdrażamy SYLION, co się zmieni, jakie korzyści” - Template FAQ dla pracowników - Talking points dla management o bezpieczeństwie danych i prywatności

Kluczowy przekaz do organizacji klienta: SYLION nie jest ograniczeniem — jest ochroną. Platforma chroni ich pracę, ich klientów i ich organizację.

107.7 Executive reporting

Comiesięczny raport executive podsumowuje stan wdrożenia, adopcji i bezpieczeństwa dla zarządu klienta.

Szablon monthly executive report:

SYLION — Monthly Executive Report Klient: [NAZWA] Okres: [MIESIĄC ROK] Przygotował: [ACCOUNT MANAGER] 1. ADOPTION SUMMARY - Licensed operators: [N] - Active operators (average daily): [N] ([%]) - New operators this month: [N] - Sessions this month: [N] 2. SECURITY EVENTS - Incidents this month: [N] (P1: [N], P2: [N], P3: [N], P4: [N]) - Notable events: [OPIS lub "Brak"] - Mean time to resolve: [CZAS] 3. SLA PERFORMANCE - Uptime: [%] (target: [%]) - Session latency p95: [MS]ms (target: <[X]ms) - CDR processing time p95: [S]s (target: <[X]s) - SLA breaches: [N] (details: [OPIS lub "Brak"]) 4. SUPPORT - Tickets this month: [N] - Average resolution time: [CZAS] - Top issues: [LISTA] 5. UPCOMING - Planned maintenance: [DATY, OPIS] - New features: [OPIS] - Recommended actions: [OPIS] 6. RECOMMENDATIONS - [Actionable recommendation 1] - [Actionable recommendation 2]

Raport dostarczany do wyznaczonego kontaktu klienta (CISO, CTO lub wskazany stakeholder) do 10. dnia kolejnego miesiąca.

107.8 Success plans

Plany sukcesu definiują długoterminową strategię współpracy z klientem, zapewniając ciągłą wartość i lojalność.

Quarterly Business Review (QBR) template:

Spotkanie QBR (60-90 minut) z klientem obejmuje: 1. Review metryk: adopcja, bezpieczeństwo, SLA (przegląd 3 monthly reports) 2. Achievement highlights: co udało się osiągnąć w kwartale 3. Challenges: problemy, eskalacje, niezadowolenie — otwarta dyskusja 4. Roadmap preview: jakie nowe funkcje/ulepszenia SYLION planuje w następnym kwartale 5. Customer roadmap alignment: czy plany klienta (growth, new offices, new use cases) wymagają zmian w konfiguracji SYLION? 6. Action items: lista działań z QBR, owner, deadline

Renewal preparation: Na 90 dni przed wygaśnięciem umowy: - Account Manager inicjuje process renewal - Przygotowanie renewal package: summary metryk z całego okresu umowy, ROI analysis (jeśli mierzalny), rekomendacja tier (utrzymanie lub zmiana) - Spotkanie renewal z klientem: review, negocjacja, finalizacja

Upsell / tier upgrade indicators: Sygnały wskazujące na gotowość klienta do przejścia na wyższy tier: - Klient pyta o features dostępne w wyższym tierze - Klient zwiększa liczbę operatorów powyżej progu - Klient ma incydent, który wyższy tier mógłby lepiej obsłużyć (np. brak Confidential Computing w STANDARD) - Zmiana profilu ryzyka klienta (nowe regulacje, nowe zagrożenia) - Klient wchodzi na nowe rynki (jurysdykcje wymagające sovereign deployment)

Account Manager powinien proaktywnie identyfikować te sygnały i proponować upgrade z uzasadnieniem biznesowym.

Rozdział 108. Materiały marketingowe i ofertowe

Status: [R] Rekomendowany Odbiorca: Marketing, Sales, Account Management, PR Wpływ na baseline: Niski Powiązane rozdziały: 107, 5

108.1 Pozycjonowanie produktu

Core positioning statement:

„Kompromitacja terminala ≠ kompromitacja danych.”

SYLION to platforma bezpiecznej komunikacji i pracy zdalnej, w której utrata, kradzież lub konfiskata urządzenia końcowego nie prowadzi do utraty danych. Dzięki architekturze thin client, Zero Trust i per-operator microVM, dane nigdy nie opuszczają chronionej infrastruktury.

Rozwinięte pozycjonowanie: SYLION jest jedyną platformą łączącą: (1) thin client terminal bez lokalnych danych, (2) per-operator izolowane microVM (Firecracker), (3) dwuwarstwowy gateway Zero Trust (G1/G2), (4) end-to-end szyfrowaną komunikację (Matrix E2EE), (5) Content Disarm and Reconstruction (CDR) dla każdego transferowanego pliku, (6) immutable audit trail (Zone 4, WORM, hash chain), (7) Confidential Computing (AMD SEV-SNP/TDX) w tierze STATE.

Key differentiator: SYLION nie jest kolejnym VPN, VDI czy komunikatorem. Jest platformą security-first, zaprojektowaną od podstaw dla osób i organizacji operujących pod podwyższonym ryzykiem — prawników, dziennikarzy, polityków, NGO i kadry zarządzającej narażonej na inwigilację, szpiegostwo przemysłowe lub ataki sponsorowane przez państwa.

Slogan (opcjonalny): „Twoje dane. Twoja kontrola. Zero kompromisów.”

108.2 Messaging by segment

Każdy segment klientów ma unikalne obawy i motywacje. Przekaz marketingowy musi być dostosowany do specyfiki segmentu.

Kancelarie prawne — ochrona tajemnicy adwokackiej: „Tajemnica adwokacka to fundament Twojej praktyki. SYLION zapewnia, że komunikacja z klientem, dokumenty procesowe i poufne materiały nigdy nie opuszczają chronionej infrastruktury — nawet jeśli Twój laptop zostanie skradziony, skonfiskowany lub zhakowany. Per-operator izolacja oznacza, że kompromitacja jednego prawnika nie zagraża sprawom innych. CDR dezinfekuje każdy plik — chronisz się przed malware ukrytym w załącznikach od klientów.”

Dziennikarze — ochrona źródeł: „Twoje źródła powierzyły Ci swoją tożsamość. SYLION chroni tę tożsamość architektonicznie, nie tylko obietnicą. Terminal thin client nie przechowuje danych — nawet przy konfiskacie przez służby nie ma czego przeszukać. E2EE oznacza, że nawet SYLION nie ma dostępu do treści Twojej komunikacji. Tryb duress pozwala na bezpieczną komunikację nawet pod przymusem. Zaprojektowane z myślą o dziennikarzach pracujących w strefach konfliktu i państwach autorytarnych.”

Politycy opozycji — bezpieczeństwo operacyjne: „Twoja komunikacja to cel obcego wywiadu. SYLION eliminuje wektory ataku, które narażają Cię na inwigilację: zero danych na urządzeniu, szyfrowanie end-to-end, Confidential Computing uniemożliwiający nawet operatorowi infrastruktury dostęp do Twoich danych. Architektura Zero Trust oznacza, że każdy komponent systemu zakłada, że pozostałe mogą być skompromitowane.”

Enterprise — ochrona IP: „Własność intelektualna to Twoja przewaga konkurencyjna. SYLION zapewnia, że poufne projekty, dane R&D i strategię biznesową są chronione przed wyciekiem — celowym (insider threat) i przypadkowym. CDR dezinfekuje każdy plik, monitoring Zone 4 wykrywa anomalie, a architektura immutable infrastructure eliminuje ryzyko persistencji atakującego.”

Rząd — suwerenność danych: „Suwerenność danych to suwerenność państwa. SYLION oferuje sovereign deployment: pełna infrastruktura pod kontrolą klienta, bez zależności od obcego cloud. AMD SEV-SNP/TDX (Confidential Computing) zapewnia, że nawet administrator infrastruktury nie ma dostępu do danych. BYO-KMS oznacza, że klucze szyfrujące są pod wyłączną kontrolą klienta. Europejska firma (Swiss AG), europejska jurysdykcja, zero US cloud dependency.”

108.3 Battlecards

SYLION vs Hypori:

Kryterium	SYLION	Hypori
Siedziba	Europa (Swiss AG)	USA
Model	Pełna platforma (komunikacja + praca zdalna + security)	Mobile VDI focus
Architektura	G1/G2 Zero Trust, per-operator microVM, CDR, Matrix	VDI z mobile thin client
Szyfrowanie	E2EE (Matrix), IPsec IKEv2, PQC-ready	Standard encryption
Confidential Computing	AMD SEV-SNP/TDX (tier STATE)	Brak
CDR	Wbudowany, każdy plik	Brak CDR
Immutable logs	Zone 4 WORM, hash chain	Standard logging
Jurysdykcja	Swiss (FDPA), brak US CLOUD Act	US (CLOUD Act)
Sovereign deployment	Tak (tier STATE)	Ograniczone

Kluczowa przewaga SYLION: europejska jurysdykcja, pełna platforma (nie tylko VDI), architektura security-first z CDR i Confidential Computing.

SYLION vs Element/Matrix:

Kryterium	SYLION	Element (Matrix)
-----------	--------	------------------

Komunikacja	Matrix E2EE (wbudowany)	Matrix E2EE
Thin client	Tak — dedykowany terminal, zero local data	Nie — aplikacja na urządzeniu użytkownika
Per-operator isolation	microVM Firecracker	Brak izolacji na poziomie użytkownika
CDR	Wbudowany	Brak
G1/G2 Zero Trust	Tak	Brak
PQC	Przygotowanie	Brak publicznie
Confidential Computing	AMD SEV-SNP/TDX	Brak
Praca zdalna	Pełna platforma (desktop, voice, file transfer)	Tylko komunikacja

Kluczowa przewaga SYLION: Element to komunikator, SYLION to pełna platforma pracy zdalnej z architekturą security-first, thin client i CDR.

SYLION vs VDI/Citrix:

Kryterium	SYLION	Citrix/VMware VDI
Cel	Security-first	Productivity-first
Architektura	Purpose-built for high risk	General purpose VDI
Izolacja	Per-operator microVM (Firecracker)	Shared infrastructure
CDR	Wbudowany	Dodatkowy product
E2EE	Matrix, voice, video	Brak natywny
Zero Trust	G1/G2 architektura	Dodatkowa konfiguracja
Thin client	Dedykowany, hardened	Standard thin client
Immutable infra	„Destroy and rebuild”	„Patch and continue”

Kluczowa przewaga SYLION: VDI jest zaprojektowane do produktywności, SYLION do bezpieczeństwa. SYLION zapewnia izolację, CDR i immutable infrastructure, które VDI nie oferuje natywnie.

108.4 One-pagery

Dla każdego segmentu klienta przygotowany jest jedno-stronicowy dokument (one-pager) podsumowujący wartość SYLION.

Struktura one-pager (per segment):

[LOGO SYLION] SYLION dla [SEGMENT] [HEADLINE — 1 zdanie, kluczowa wartość] PROBLEM: [2-3 zdania opisujące zagrożenia specyficzne dla segmentu] ROZWIĄZANIE: [3-4 bullet points opisujące jak SYLION adresuje te zagrożenia] ARCHITEKTURA (diagram uproszczony): [Terminal] → [Encrypted tunnel] → [G1/G2] → [microVM] → [Dane chronione] KLUCZOWE CECHY: • Thin client — zero danych na urządzeniu • Per-operator microVM — izolacja pełna • E2EE — szyfrowanie end-to-end • CDR — dezynfekcja plików • Zone 4 — immutable audit trail • [CECHY SPECYFICZNE DLA SEGMENTU] TIER RECOMMENDATION: [STANDARD / PRO / STATE] KONTAKT: sales@sylion.ch | +41 XXX XXX XXX

One-pagery per segment: - Kancelarie prawne: focus na tajemnicę adwokacką, CDR, izolację per-prawnik - Dziennikarze: focus na ochronę źródeł, duress mode, brak danych na terminalu - Enterprise: focus na IP protection, insider threat, compliance - Rząd/Government: focus na suwerenność, sovereign deployment, Confidential Computing, brak US cloud

108.5 Decki sprzedażowe

Struktura prezentacji sprzedażowej (deck) powinna prowadzić odbiorcę od problemu przez rozwiązanie do decyzji.

Rekomendowana struktura deck (15-20 slajdów):

Titlujący (1 slajd): SYLION — [tagline per segment]

Problem (2-3 slajdy):

Krajobraz zagrożeń: statystyki, przykłady (anonimizowane)

Dlaczego obecne narzędzia nie wystarczają (VPN, email, VDI — luki)

Konsekwencje: utrata danych, naruszenie tajemnicy, kary regulacyjne

Rozwiązanie (2 slajdy):

Core concept: „Kompromitacja terminala ≠ kompromitacja danych”

Architektura high-level (uproszczony diagram)

Architektura (3-4 slajdy):

Thin client + Zero Trust (G1/G2)

Per-operator microVM (Firecracker)

E2EE (Matrix) + CDR

Zone 4 (immutable logs)

Confidential Computing (jeśli tier STATE)

Security depth (2-3 slajdy):

Scenariusze ataku i jak SYLION je neutralizuje:

Kradzież terminala → zero danych

Malware w załączniku → CDR

Insider threat → izolacja + monitoring

Serwer skompromitowany → „destroy and rebuild”

Compliance (1-2 slajdy):

GDPR, NIS2, certyfikacje

Jurysdykcja Swiss AG

Audit readiness

Pricing (1 slajd):

STANDARD: 400€/user

PRO: 1500€/user

STATE: 2500€/user (min 50)

Co zawiera każdy tier (feature matrix)

References (1 slajd):

Testimonials / case studies (anonimizowane jeśli klient nie zgodzi się na ujawnienie)

Next steps (1 slajd):

Discovery call → Assessment → Pilot (30 dni) → Rollout

CTA: „Umów demo”

Zasady prezentacji: - Minimalizm: max 5 bullet points na slajd, duża czcionka - Diagramy zamiast tekstu gdzie możliwe - Brak żargonu technicznego w sekcjach problem/rozwiązanie (audience = management) - Sekcja architektura: dostosowanie głębokości do odbiorcy (CISO chce szczegółów, CEO chce big picture)

108.6 Tabela przewag konkurencyjnych

Macierz porównawcza SYLION z głównymi konkurentami:

Cecha	SYLION	Hypori	Element/Matrix	Citrix VDI	ZTNA (Zscaler/Cloudflare)
Thin client (zero local data)	✓ Dedykowany	✓ Mobile	✗ App na urządzeniu	Częściowy	✗
Per-operator microVM	✓ Firecracker	✗	✗	✗ Shared	✗
G1/G2 Zero Trust gateway	✓	✗	✗	✗	Częściowy (ZTNA)
E2EE messaging	✓ Matrix	✗	✓ Matrix	✗	✗
E2EE voice/video	✓	✗	✓	✗	✗
CDR (Content Disarm)	✓ Wbudowany	✗	✗	Osobny produkt	✗
Immutable logs (WORM)	✓ Zone 4, hash chain	✗	✗	✗	Częściowy
Confidential Computing	✓ SEV-SNP/TDX (STATE)	✗	✗	✗	✗
PQC ready	✓	✗	✗	✗	Częściowy
Sovereign deployment	✓ (STATE)	Ograniczone	Self-host możliwy	On-prem możliwy	✗ (cloud)
Europejska jurysdykcja	✓ Swiss AG	✗ (US)	✓ (UK)	✗ (US)	✗ (US)
BYO-KMS	✓ (STATE)	✗	✗	✗	✗
Duress mode	✓	✗	✗	✗	✗
HSM/PKI natywne	✓	✗	✗	✗	✗
Immutable infrastructure	✓ „Destroy and rebuild”	✗	✗	✗	✗
Pełna platforma pracy	✓ (desktop + comms + file)	Częściowy	✗ (tylko comms)	✓ (desktop)	✗ (access)

Legenda: ✓ = natywnie obsługiwane, ✗ = nieobsługiwane, Częściowy = wymaga dodatkowej konfiguracji lub osobnego produktu.

108.7 FAQ sprzedaży

Q: Czy możecie zagwarantować 100% bezpieczeństwa? Nie — i nikt uczciwy tego nie zagwarantuje. SYLION minimalizuje blast radius każdego incydentu: kompromitacja terminala nie oznacza utraty danych, kompromitacja jednego workloadu nie zagraża innym, kompromitacja serwera wymaga odbudowy (nie łątania). Każda warstwa systemu zakłada, że inne mogą być skompromitowane.

Q: Czy to jest legalne? Tak. Wszystkie kluczowe komponenty SYLION (szyfrowanie, VPN, thin client) są legalne w Europie, USA i większości jurysdykcji. Certyfikowalne komponenty bazowe (Matrix, Firecracker, IPsec IKEv2) są szeroko używane i audytowane. W jurysdykcjach z ograniczeniami szyfrowania (niektóre kraje Bliskiego Wschodu, Azji) — konsultacja z lokalnymi regulacjami przed wdrożeniem.

Q: A co z GDPR? Swiss AG (SYLION AG) działa jako processor w rozumieniu GDPR. Data Processing Agreement (DPA) jest częścią umowy. Rezydencja danych jest konfigurowalna (wybór regionu). Dla tier STATE: sovereign deployment eliminuje zależność od obcych jurysdykcji. SYLION wspiera klienta w spełnieniu obowiązków

GDPR (Art. 28, 32, 33).

Q: Czy możemy to hostować sami? Tak — sovereign deployment jest dostępny w tierze STATE. Pełna infrastruktura pod kontrolą klienta, na serwerach klienta, z BYO-KMS i Confidential Computing. SYLION zapewnia deployment, szkolenie i wsparcie, ale dane i klucze są pod wyłączną kontrolą klienta.

Q: Dlaczego jest to tak drogie? Cena odzwierciedla: (1) per-operator izolację (dedykowana microVM — nie shared resources), (2) dedykowany hardware terminal + router, (3) architekturę security-first (CDR, G1/G2, Zone 4, HSM), (4) wsparcie 24/7 dla incydentów bezpieczeństwa. Porównanie z kosztem wycieku danych, naruszenia tajemnicy adwokackiej lub kompromitacji źródła dziennikarskiego — SYLION jest inwestycją w ochronę.

Q: Jaki jest czas wdrożenia? Typowy timeline: Discovery (1 tydzień) → Assessment (1 tydzień) → Pilot 30 dni → Rollout (4-8 tygodni). Od podpisania umowy do pełnej operacyjności: 10-14 tygodni. Dla tier STATE z sovereign deployment: 16-20 tygodni.

Q: Co jeśli internet jest niestabilny? Router SYLION zapewnia szyfrowane połączenie, ale wymaga dostępu do internetu (minimum 10 Mbps na operatora). W przypadku utraty łączności: sesja jest zawieszona, ale dane są bezpieczne (w microVM). Po przywróceniu łączności: reconnect. Dla lokalizacji z niestabilnym internetem: rekomendujemy redundantne łącze.

108.8 Oświadczenia ostrożności i ograniczeń

SYLION jest zobowiązany do uczciwej komunikacji swoich możliwości i ograniczeń. Poniższe oświadczenia muszą być dostępne dla klientów i potencjalnych klientów.

Czego SYLION NIE chroni:

Błąd operatora (operator error): Jeśli operator dobrowolnie udostępni swoje dane, wyśle poufne informacje nieautoryzowanemu odbiorcy lub zignoruje procedury bezpieczeństwa — SYLION nie może temu zapobiec. System zapewnia narzędzia i kontrole, ale ostateczna odpowiedzialność za działania leży po stronie operatora. SYLION minimalizuje konsekwencje błędów (np. CDR chroni przed nieświadomym wysłaniem zainfekowanego pliku), ale nie eliminuje ludzkiego czynnika.

Fizyczny przymus z dobrowolną współpracą operatora: Jeśli operator pod fizycznym przymusem dobrowolnie współpracuje z atakującym (podaje PIN, weryfikuje urządzenie, nawiązuje sesję), SYLION nie może odróżnić tego od normalnego użycia — chyba że operator aktywuje tryb duress. SYLION zapewnia mechanizm duress, ale nie może wymusić jego użycia.

Komputery kwantowe łamiące istniejący ruch (pre-PQC): Ruch szyfrowany przed wdrożeniem Post-Quantum Cryptography (PQC) może być w przyszłości odszyfrowany przez komputery kwantowe (harvest now, decrypt later). SYLION jest w trakcie wdrażania PQC, ale ruch historyczny (sprzed PQC upgrade) nie jest chroniony przed tym wektorem. Minimalizacja: efemeryczne klucze sesji nie są przechowywane — atakujący musiałby przechwycić ruch na żywo.

Fizyczny dostęp do HSM przez aktor state-level: Atakujący z fizycznym dostępem do modułów HSM (np. w scenariuszu przeszukania data center przez agencję rządową z jurysdykcją) może potencjalnie uzyskać dostęp do kluczy. Minimalizacja: sovereign deployment (tier STATE) umożliwia klientowi kontrolę fizyczną nad HSM. HSM z certyfikacją FIPS 140-3 Level 3+ zapewnia odporność na physical tampering.

Ataki side-channel na Confidential Computing: AMD SEV-SNP i Intel TDX, choć znacząco podnoszą bezpieczeństwo, nie są wolne od teoretycznych ataków side-channel (udowodnionych w środowisku badawczym). SYLION monitoruje stan badań i wdraża mitygacje, ale nie może zagwarantować odporności na przyszłe, nieznane ataki tego typu.

Kompromitacja łańcucha dostaw powyżej kontroli SYLION: Jeśli hardware (CPU, memory, firmware) jest skompromitowany na etapie produkcji (supply chain attack na poziomie krzemowym), SYLION nie może tego wykryć ani zapobiec. Minimalizacja: weryfikacja dostawców, SBOM, SLSA.

Honest capability statement:

SYLION zapewnia architekturę, która dramatycznie ogranicza blast radius każdego incydentu bezpieczeństwa. Nie obiecujemy, że atak jest niemożliwy — obiecujemy, że skutki ataku są ograniczone do minimum dzięki izolacji, szyfrowaniu i immutable infrastructure. Każda warstwa systemu jest zaprojektowana z założeniem, że inne warstwy mogą zawieść.

SYLION jest narzędziem — nie magią. Wymaga przeszkolonych operatorów, kompetentnych administratorów i dojrzałych procesów bezpieczeństwa po stronie klienta. Wspieramy klientów w budowaniu tych kompetencji (Rozdział 105, 107), ale bezpieczeństwo jest procesem współdzielonym.

partnerów Właściciel dokumentu: Architekt Główny SYLION

CZĘŚĆ XIV — INFRASTRUKTURA I WDROŻENIA

Rozdział 109. Wzorce wdrożeniowe infrastruktury

109.1 Kubernetes — kiedy stosować, a kiedy nie

Status: [R] Rekomendowany Odbiorca: Infra | Architekt | Dev | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 109.2, 109.3, 109.7, 109.8, 113.1

Kubernetes stanowi de facto standard orkiestracji kontenerów w środowiskach chmurowych i w ekosystemie SYLION pełni wyraźnie zdefiniowaną rolę — jest platformą zarządzania control plane'em i usługami współdzielonymi, lecz nie jest środowiskiem uruchomieniowym dla workloadów operatorskich. Rozróżnienie to ma fundamentalne znaczenie architektoniczne i bezpieczeństwa.

Kiedy Kubernetes jest właściwy. Kubernetes powinien być stosowany w Strefie 4 (usługi współdzielone) oraz Strefie 5 (płaszczyzna zarządzania) do orkiestracji komponentów takich jak: SIEM/monitoring (Prometheus + Grafana + Loki), IAM (Keycloak), PKI management, serwery konfiguracyjne, pipeline'y CI/CD, systemy audytowe, usługi webhookowe oraz panele administracyjne. W tych zastosowaniach Kubernetes zapewnia: automatyczne skalowanie horyzontalne, self-healing (restart crashujących podów), rolling update bez downtime'u, deklaratywną konfigurację, wbudowaną obsługę secrets (integracja z Vault), network policies (Calico/Cilium) oraz natywną integrację z ekosystemem CNCF.

Kubernetes zarządza również klastrem management — centralnym punktem kontroli infrastruktury. Klaster management obsługuje Terraform controller, ArgoCD (GitOps), Vault operator, cert-manager oraz monitoring stack. Klaster ten musi być odizolowany sieciowo od klastrów workloadowych i dostępny wyłącznie z management VPN.

Kiedy Kubernetes NIE jest właściwy. Workloady operatorskie (Strefa 3) nie powinny być uruchamiane jako kontenery w Kubernetes. Kontenery współdzielą kernel hosta — nawet z mechanizmami izolacji (seccomp, AppArmor, gVisor) — co stanowi niedopuszczalny profil ryzyka dla per-operator workloadów SYLION. Przełamanie izolacji kontenera umożliwia dostęp do workloadów innych operatorów na tym samym hoście. Firecracker microVM (109.3) oferuje izolację na poziomie hiperwizora z 5 emulowanymi urządzeniami, eliminując ten wektor ataku. Kubernetes nie powinien również być stosowany tam, gdzie wymagana jest izolacja kryptograficzna per-tenant na poziomie hypervisora — w szczególności w deploymentach STATE z AMD SEV-SNP/Intel TDX.

Wyjątek stanowią deploymenty STANDARD z akceptowalnym profilem ryzyka, gdzie klient świadomie zaakceptował model współdzielonego klastra z network policies (109.8). W takim przypadku Kubernetes może zarządzać workloadami, ale musi to być udokumentowane jako odstępstwo od baseline'u architektonicznego.

109.2 VM-based — tradycyjne wdrożenia maszynami wirtualnymi

Status: [R] Rekomendowany Odbiorca: Infra | Architekt | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 109.1, 109.3, 109.6, 110.1, 112.1

Tradycyjne maszyny wirtualne (KVM/QEMU, VMware ESXi, Hyper-V) stanowią sprawdzony i dobrze rozumiany model deploymentu, który w architekturze SYLION pełni kluczową rolę dla komponentów wymagających pełnej izolacji systemowej, stabilnego środowiska i długoterminowej trwałości konfiguracji. Model VM-based jest preferowany dla bramek G1/G2, serwerów HSM, węzłów management plane oraz komponentów, których cykl życia mierzony jest w miesiącach lub latach, a nie w minutach.

Bramki G1 (Ingress Gateway). G1 działa jako jedyny punkt wejścia do infrastruktury SYLION i realizuje terminację IPsec IKEv2, inspekcję pakietów (w granicach dozwolonych przez model Zero Trust), load balancing do węzłów G2 oraz ochronę DDoS na warstwie sieciowej. G1 musi działać na dedykowanej VM z pełną kontrolą nad konfiguracją sieciową (multiple NICs, custom routing, IP failover). Kubernetes pod nie zapewnia tego poziomu kontroli sieci bez złożonych workarounds (host networking, privileged containers), które same stanowią ryzyko.

Bramki G2 (Session Gateway). G2 zarządza sesjami operatorskimi, przekierowuje ruch do odpowiednich microVM (Strefa 3) i realizuje policy enforcement. G2 wymaga niskiego i przewidywalnego opóźnienia — VM z dedykowanymi zasobami CPU (pinning) i RAM zapewnia determinizm wydajnościowy nieosiągalny w środowisku Kubernetes z cooperation scheduling.

Serwery HSM. Hosty fizyczne lub dedykowane VM z passthrough do urządzeń HSM (USB/PCIe). Kubernetes nie powinien zarządzać hostami HSM — restart poda z HSM passthrough jest ryzykowny i wymaga sekwencji reinicjalizacji kryptograficznej.

Węzły management plane. Serwery Vault, Primary CA, Master Database — komponenty, których restart lub migracja musi być w pełni kontrolowany przez operatora ludzkiego, a nie przez scheduler Kubernetes. Vault w trybie HA wymaga precyzyjnej sekwencji unseal, co koliduje z modelem pod eviction.

Kiedy preferować VM nad microVM. VM-based jest właściwy, gdy: workload wymaga pełnego systemu operacyjnego z wieloma usługami, cykl życia jest długi (tygodnie+), wymagany jest passthrough urządzeń hardware, workload potrzebuje więcej niż 5 emulowanych urządzeń (limit Firecracker), lub gdy wymagana jest kompatybilność ze starszym oprogramowaniem (legacy VPN appliances, specyficzne moduły jądra). VM-based wiąże się z wyższym kosztem zasobów per instancja i dłuższym czasem startu (sekundy-minuty vs <150ms dla Firecracker), ale oferuje większą elastyczność konfiguracyjną.

109.3 MicroVM-based — Firecracker dla workloadów operatorskich

Status: [N] Normatywny Odbiorca: Infra | Architekt | Dev | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 109.1, 109.2, 109.6, 109.8, 112.1, 112.7

Firecracker microVM stanowi normatywny model uruchomieniowy dla workloadów operatorskich w Strefie 3 systemu SYLION. Każdy operator otrzymuje dedykowaną microVM, co realizuje fundamentalną zasadę architektury: izolacja per-operator na poziomie hiperwizora. Firecracker został wybrany ze względu na unikalną kombinację właściwości bezpieczeństwa i wydajności, które żaden inny model wdrożeniowy nie zapewnia jednocześnie.

Architektura Firecracker. Firecracker to open-source Virtual Machine Monitor (VMM) stworzony przez AWS, wykorzystujący KVM jako hiperwizor. Kluczowa cecha: każda microVM ekspozuje wyłącznie 5 emulowanych urządzeń — virtio-net (sieć), virtio-block (dysk), serial console, 1-button keyboard controller i minimalny i8042. Minimalna powierzchnia ataku oznacza, że przełamanie izolacji microVM wymaga znalezienia exploita w jednym z tych 5 urządzeń — porównaj z QEMU, który emuluje setki urządzeń. Firecracker nie obsługuje GPU passthrough, PCI passthrough, USB ani żadnych dodatkowych urządzeń, co jest zamierzoną decyzją architektoniczną eliminującą wektory ataku.

Właściwości bezpieczeństwa. (a) Izolacja per-operator — kompromitacja jednego workloadu nie daje dostępu do workloadów sąsiednich. (b) Jailer — Firecracker uruchamiany jest w dedykowanym namespace z seccomp filtrem (dozwolone ~25 syscalls z ~300+), cgroups limits i chroot. (c) Brak dostępu do hosta — microVM nie ma mechanizmu breakout do host OS poza zdefiniowanymi interfejsami virtio. (d) Ephemeral nature — microVM może być tworzona i niszczone w milisekundach, wspierając model „use-once” dla sesji o podwyższonym ryzyku.

Wydajność. Czas startu microVM: <150ms (cold boot z vmlinux + rootfs). Czas zniszczenia: <10ms. Overhead pamięci: ~5MB na microVM (sam VMM). Density: na hoście z 64GB RAM i 16 vCPU możliwe jest uruchomienie 200+ microVM jednocześnie (zakładając 256MB RAM per microVM). Boot time umożliwia model on-demand provisioning — microVM tworzona jest w momencie połączenia operatora i niszczone po zakończeniu sesji.

Model lifecycle. (1) Operator uwierzytelnia się przez G1/G2 → (2) Orchestrator (Strefie 5) prowizjonuje Firecracker microVM z pre-built rootfs + overlay → (3) microVM otrzymuje dedykowany TAP interface z VLAN/namespace izolacją → (4) Operator połączony jest z microVM przez Guacamole (remote desktop) lub terminal SSH → (5) Po zakończeniu sesji microVM jest niszczone, rootfs overlay usuwany, a audit log kompletowany. Model ten zapewnia czystość kryptograficzną — każda sesja startuje z czystego stanu (no persistence between sessions) o ile operator nie ma przypisanego persistent volume.

Integracja z AMD SEV-SNP / Intel TDX (STATE). Dla tieru STATE, Firecracker microVM mogą być uruchamiane wewnątrz Confidential VM, zapewniając szyfrowanie pamięci per-VM z kluczami zarządzanymi przez procesor (nie przez hiperwizora). To dodaje warstwę ochrony przed złośliwym administratorem hosta lub kompromitacją hiperwizora.

109.4 Serverless — przetwarzanie funkcyjne tam, gdzie to właściwe

Status: [O] Opcjonalny Odbiorca: Infra | Architekt | Dev Wpływ na baseline: Niski Powiązane rozdziały: 109.1, 109.6, 112.1, 112.8

Model serverless (Function-as-a-Service) ma ograniczone, ale uzasadnione zastosowania w ekosystemie SYLION — głównie dla krótkotrwałych, bezstanowych zadań przetwarzania, które nie wymagają izolacji per-operator ani dostępu do wrażliwych danych operatorskich. Serverless NIE jest właściwy dla żadnego komponentu na ścieżce krytycznej bezpieczeństwa.

Zastosowania uzasadnione. (a) Przetwarzanie CDR (Content Disarm & Reconstruction) — funkcje Lambda/Cloud Functions uruchamiane przez event z kolejki (SQS/Pub-Sub), przetwarzające pojedyncze pliki. Każde wywołanie jest bezstanowe, izolowane i automatycznie skalowalne. CDR wymaga CPU burst (dekompresja, parsing, rekonstrukcja) na krótkie okresy — idealny profil dla serverless. (b) Webhook handlers — obsługa zdarzeń zewnętrznych (alerty monitoringu, notyfikacje CI/CD, callback z dostawców usług). (c) Scheduled jobs — raporty compliance, generowanie kosztów, rotacja temporary credentials, cleanup expired sessions. (d) Email/notification delivery — bezstanowe wysyłanie powiadomień o incydentach, alertów SLA, raportów. (e) Log processing pipelines — transformacja i enrichment logów przed załadowaniem do SIEM.

Ograniczenia i ryzyka. Serverless w kontekście SYLION niesie specyficzne ryzyka: (1) Cold start latency (100ms-2s) — niedopuszczalne na ścieżce krytycznej sesji operatorskiej. (2) Vendor lock-in — Lambda-specific code jest trudniejszy do migracji niż kontenery. (3) Brak kontroli nad runtime — provider zarządza środowiskiem wykonawczym, co komplikuje audyt bezpieczeństwa. (4) Debugging złożoność — rozproszone śledzenie (tracing) jest trudniejsze niż w monolitycznych serwisach. (5) Ograniczenia timeout — większość platform FaaS ogranicza wykonanie do 15 minut, co wyklucza długotrwałe procesy.

Wymagania bezpieczeństwa. Funkcje serverless w SYLION muszą: nie przetwarzać danych operatorskich (content) — wyłącznie metadane i pliki w pipeline CDR; być deployowane z VPC integration (prywatna sieć, brak publicznego dostępu); logować każde wywołanie do centralnego systemu audytu; wykorzystywać IAM role z minimalnym zakresem uprawnień (principle of least privilege); być wersjonowane i deployowane wyłącznie przez CI/CD pipeline z code signing.

109.5 Bare-metal — dedykowane serwery fizyczne

Status: [R] Rekomendowany (STATE) | [O] Opcjonalny (PRO/STANDARD) Odbiorca: Infra | Architekt | SOC | Compliance Wpływ na baseline: Wysoki (STATE) Powiązane rozdziały: 109.2, 109.3, 109.6, 111.6, 119.2

Bare-metal — serwery fizyczne bez warstwy wirtualizacji dostawcy chmurowego — stanowi wymagany model deploymentu dla komponentów o najwyższych wymaganiach bezpieczeństwa, wydajności i kontroli. W architekturze SYLION bare-metal jest normatywny dla hostów HSM w tierze STATE oraz rekomendowany dla management plane i G1 w deploymentach STATE/SOVEREIGN.

Hosty HSM. Hardware Security Module (FIPS 140-3 Level 3) wymaga fizycznego połączenia z hostem (PCIe lub USB) oraz fizycznego zabezpieczenia przed tampering. HSM nie może być deployowany w VM w chmurze publicznej, ponieważ: (a) dostawca chmury kontroluje hypervisor i może potencjalnie przechwytywać komunikację host-HSM, (b) migracja VM (live migration) mogłaby odłączyć HSM od hosta, powodując utratę sesji kryptograficznych, (c) fizyczne bezpieczeństwo HSM wymaga kontroli dostępu do serwerowni (klucze, kamery, audit trail), co jest możliwe wyłącznie w kontrolowanych lokalizacjach. Dla tieru STATE bare-metal z HSM musi być deployowany w certyfikowanym centrum danych z normą minimum EN 50600 Class 3 lub ANSI/TIA-942 Tier III.

Management plane (STATE). Vault HA cluster, Primary CA, Master Database mogą być deployowane na bare-metal dla eliminacji ryzyka hypervisor-level attack. W modelu Confidential Computing (AMD SEV-SNP) hypervisor dostawcy chmury jest w granicach zaufania — bare-metal eliminuje tę zależność. Management plane na bare-metal wymaga: RAID 10 dla storage (wydajność + redundancja), ECC RAM (ochrona przed bit-flip), IPMI/iLO dla out-of-band management (zabezpieczone osobną siecią VLAN), TPM 2.0 dla measured boot i secure boot chain.

G1 performance-critical. Bramki G1 obsługujące tysiące jednoczesnych sesji IPsec mogą wymagać bare-metal ze względu na: DPDK (Data Plane Development Kit) dla wysokowydajnego przetwarzania pakietów, SR-IOV dla bypass hypervisora na NIC, crypto offload hardware (Intel QAT, AES-NI). Bare-metal G1 osiąga 10-40 Gbps throughput IPsec vs 2-5 Gbps w VM bez hardware offload.

Koszt i zarządzanie. Bare-metal jest droższy niż VM/microVM: typowy serwer dedykowany kosztuje 200-500€/miesiąc vs 60€ za VPS. Zarządzanie wymaga Ansible/Terraform dla provisioning, PXE boot dla instalacji OS, i out-of-band management dla recovery. Uzasadnione ekonomicznie dopiero przy tierze STATE (2500€/user, min 50 users = 125K€+ rocznie przychodu, przy czym infrastruktura bare-metal dla 50 userów kosztuje ~5-10K€/miesiąc).

109.6 Architektura hybrydowa — łączenie modeli wdrożeniowych

Status: [N] Normatywny Odbiorca: Infra | Architekt | Dev | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 109.1–109.5, 109.7, 110.1

Produkcyjna infrastruktura SYLION nigdy nie jest jednorodna — każde wdrożenie łączy co najmniej dwa, typowo trzy lub cztery modele wdrożeniowe, dopasowując typ compute do profilu bezpieczeństwa, wydajności i kosztu każdej strefy. Architektura hybrydowa jest normatywna, ponieważ żaden pojedynczy model nie spełnia jednocześnie wszystkich wymagań systemu.

Referencyjny model hybrydowy (STANDARD):

Strefa	Komponent	Model	Uzasadnienie
0	Terminal operatora	Pixel (hardware)	Dedykowane urządzenie, GrapheneOS
1	Router dostępowy	GL-iNet (hardware)	IPsec termination, fizyczna izolacja sieci
2	G1/G2 gateways	VM (VPS)	Dedykowane zasoby, kontrola sieci
3	Workload operatorski	Firecracker microVM	Per-operator izolacja, <150ms boot
4	Usługi współdzielone	Kubernetes	Auto-scaling, self-healing, GitOps
5	Management plane	VM (dedicated)	Stabilność, kontrola lifecycle
—	CDR processing	Serverless (opcjonalnie)	Burst processing, bezstanowe

Model STATE/SOVEREIGN:

Strefa	Komponent	Model	Uzasadnienie
2	G1/G2	Bare-metal lub dedicated VM	Wydajność, brak hypervisor trust
3	Workload operatorski	Firecracker + SEV-SNP	Confidential Computing, per-operator izolacja
4	Usługi współdzielone	Dedykowany Kubernetes cluster	Cluster-per-tenant izolacja
5	Management plane	Bare-metal	HSM, Vault, eliminacja cloud trust
5	HSM	Bare-metal (obowiązkowy)	Fizyczne bezpieczeństwo kluczy

Zasady łączenia modeli. (1) Granice stref definiują granice modeli — nie mieszać modeli wdrożeniowych w obrębie jednej strefy bez uzasadnienia architektonicznego. (2) Komunikacja między modelami odbywa się wyłącznie przez zdefiniowane interfejsy (API, message queue, network policy) — nigdy przez współdzielony filesystem lub pamięć. (3) Każdy model wymaga dedykowanego monitoringu i alertów — metryki Kubernetes, metryki Firecracker VMM, metryki VM i metryki bare-metal zbierane są przez osobne exportery i korelowane w centralnym SIEM. (4) Deployment i lifecycle management jest unified przez IaC (Terraform + Ansible), niezależnie od modelu — brak ręcznych konfiguracji.

Deployment consistency. Hybrid deployment wymaga spójnej warstwy abstrakcji, aby zespoły operacyjne nie musiały znać szczegółów każdego modelu. SYLION stosuje Terraform modules per model wdrożeniowy z zunifikowanym interfejsem wejścia/wyjścia (input: CPU, RAM, network, security_profile; output: endpoint, monitoring_target, log_destination). Ansible role są parametryzowane per model (hardening_profile: firecracker | vm | baremetal | k8s_pod).

109.7 Wzorce multi-cluster — klastry zarządzania i workloadowe

Status: [R] Rekomendowany Odbiorca: Infra | Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 109.1, 109.6, 109.8, 110.1, 113.1

Architektura multi-cluster rozdziela płaszczyznę zarządzania od płaszczyzny workloadów, zapewniając, że kompromitacja jednego klastra nie daje bezpośredniego dostępu do drugiego. W SYLION obowiązuje model minimum dwóch klastrów Kubernetes: klaster management i klaster workload. Dla deploymentów multi-region lub multi-tenant liczba klastrów rośnie proporcjonalnie.

Klaster management. Centralny klaster zarządzający całością infrastruktury. Zawiera: ArgoCD (GitOps controller deployujący konfigurację do wszystkich klastrów), Vault (secrets management, PKI, dynamic credentials), Prometheus/Thanos (cross-cluster monitoring), Grafana (dashboards), Loki (centralne logi), Terraform Cloud Agent (IaC execution), CI/CD runners (build + deploy), Policy engine (OPA/Gatekeeper). Klaster management nie obsługuje żadnych workloadów operatorskich ani usług bezpośrednio dostępnych dla operatorów. Dostęp wyłącznie przez VPN management z MFA + FIDO2. Klaster management musi być deployowany w regionie zarządzanym bezpośrednio przez SYLION (nie w regionie klienta).

Klastry workload. Klastry obsługujące usługi Strefy 4 (monitoring per-region, session broker, CDR pipeline, cache) oraz orkiestrujące Firecracker microVM Strefy 3 (przez API, nie jako pody). Klastry workload są per-region i per-tier-group. Klaster workload nie ma dostępu do konfiguracji management — pull model (ArgoCD synchronizuje konfigurację), nie push.

Cross-cluster networking. Komunikacja między klastrem management a klastrami workload odbywa się przez dedykowane łącza prywatne (VPC peering lub transit gateway), zaszyfrowane IPsec/WireGuard. Brak routingu przez publiczny internet. Każdy klaster workload ma ograniczony zestaw endpointów management, do których może się łączyć (Vault API, ArgoCD webhook, monitoring push endpoint) — whitelist, nie blacklist.

Scaling pattern. Nowy region → nowy klaster workload, połączony z centralnym management. Nowy klient STATE → nowy dedykowany klaster workload (cluster-per-tenant). Nowy klient STANDARD → workload deployowany do istniejącego klastra regional z namespace isolation. Ten model pozwala skalować horyzontalnie bez złożoności jednego mega-klustra. Klaster management skaluje wertykalnie (więcej zasobów) z HA (3+ control plane nodes).

Disaster recovery. Klaster management posiada passive standby w drugim regionie, z asynchroniczną replikacją stanu (etcd snapshot + Vault replication). RTO dla management: <30 minut (failover do standby). Klastry workload są niezależne — awaria klastra management nie wpływa na działające workloady operatorskie, jedynie na możliwość provisioningu nowych i zmian konfiguracji.

109.8 Modele izolacji tenantów

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC | Compliance | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 109.1, 109.3, 109.7, 110.5, 119.2, 120.1

Izolacja tenantów jest jednym z fundamentalnych wymagań bezpieczeństwa SYLION i jest realizowana na trzech poziomach w zależności od tieru usługi. Każdy model gwarantuje, że dane i workloady jednego klienta (tenanta) są niedostępne dla innego — różnica polega na głębokości izolacji i kosztach.

Cluster-per-tenant (STATE/SOVEREIGN). Każdy klient STATE otrzymuje dedykowany klaster Kubernetes (lub dedykowaną infrastrukturę bare-metal/VM) z pełną izolacją: dedykowane węzły compute, dedykowana sieć (VLAN/VPC), dedykowany storage, dedykowane HSM partition (lub dedykowany HSM fizyczny), dedykowane klucze szyfrujące, dedykowany monitoring. Żaden komponent nie jest współdzielony z innymi tenantami. Klaster-per-tenant eliminuje wszelkie noisy-neighbor efekty, side-channel attacks na współdzielonym hardware, oraz ryzyko błędu konfiguracyjnego otwierającego dane jednego tenanta drugiemu.

Koszt: ~3-5x wyższy niż model współdzielony (dedykowane węzły, dedykowana sieć, dedykowane zarządzanie). Uzasadniony przy cenie STATE 2500€/user × min 50 users = 125K€+ rocznie. Dedykowany klaster dla 50 użytkowników kosztuje ~3-5K€/miesiąc infrastruktury = ~40-60K€ rocznie, co przy przychodzie 125K€+ daje zdrową marżę.

Namespace-per-tenant (PRO). Klienci PRO współdzielą klaster Kubernetes, ale każdy tenant otrzymuje dedykowany namespace z: ResourceQuota (gwarantowane zasoby CPU/RAM), NetworkPolicy (tenant A nie może komunikować się z tenant B), dedykowane ServiceAccount, per-tenant secrets (klucze szyfrujące z Vault, per-tenant KV store), per-tenant monitoring labels. MicroVM operatorskie nadal zapewniają izolację per-operator w ramach tenanta.

Izolacja namespace jest wystarczająca dla klientów korporacyjnych (PRO), ale nie spełnia wymagań deploymentów rządowych/obronnych. Ryzyka rezydualne: współdzielony kernel węzłów Kubernetes (mitigowane przez Firecracker dla workloadów), współdzielony etcd (mitigowane przez encryption-at-rest per-tenant prefix), potencjalne side-channel attacks na współdzielonym CPU (mitigowane przez CPU pinning per-tenant).

Shared-with-network-isolation (STANDARD). Klienci STANDARD współdzielą infrastrukturę z izolacją sieciową: dedykowane network policies per tenant, per-operator Firecracker microVM, per-tenant encryption keys. Współdzielone: klaster Kubernetes, monitoring infrastructure, G1/G2 (z per-session routing). Model ten zapewnia bezpieczeństwo wystarczające dla kancelarii prawnych, dziennikarzy, NGO — ochrona przed atakami spoza systemu i przed innymi operatorami, ale nie przed zaawansowanym adwersarzem z dostępem do infrastruktury.

Matryca izolacji:

Aspekt	STANDARD	PRO	STATE
Compute	MicroVM per-op	MicroVM per-op	Dedicated cluster
Network	Network policy	Namespace + NP	Dedicated VPC
Storage	Per-tenant keys	Per-tenant keys	Dedicated storage
HSM	Shared partition	Dedicated partition	Dedicated HSM
Monitoring	Shared + labels	Per-tenant dashboards	Dedicated stack
Management	Shared	Shared + delegation	Dedicated

Rozdział 110. Architektura sieciowa i multi-region

110.1 Region primary/secondary — modele active-passive i active-active

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 109.6, 109.7, 110.2, 110.4, 110.9, 112.4

Architektura multi-region SYLION stosuje dwa modele dostępności w zależności od tieru usługi: active-passive dla STANDARD/PRO oraz active-active dla STATE. Wybór modelu determinuje koszty, złożoność, czas failover oraz wymagania dotyczące synchronizacji danych.

Active-passive (STANDARD/PRO). Region primary obsługuje cały ruch operatorski. Region secondary utrzymuje repliki konfiguracji, IAM, PKI state i backupów — ale nie obsługuje aktywnych sesji. W przypadku awarii regionu primary następuje failover: (1) monitoring wykrywa niedostępność primary (health check failure po 3 × 10s = 30s), (2) orchestrator inicjuje failover (automatyczny dla P1, manualny approval dla P2-P4), (3) DNS update lub BGP withdrawal przekierowuje ruch do secondary, (4) secondary promowane do primary — microVM provisionowane od nowa, sesje operatorskie muszą być ponownie nawiązane.

Czas failover: target <5 minut dla STANDARD, <2 minuty dla PRO. RPO (Recovery Point Objective): STANDARD 15 minut (async replication), PRO 1 minuta (near-sync replication). RTO (Recovery Time Objective): STANDARD 10 minut, PRO 5 minut.

Active-active (STATE). Oba regiony obsługują ruch jednocześnie. Operator jest przypisany do regionu primary (ze względu na data residency), ale sesje mogą być obsługiwane przez region secondary w przypadku degradacji primary. Wymaga: synchronicznej replikacji IAM/config state (Raft consensus między regionami, latencja <50ms wymagana), per-operator affinity routing (operator zawsze kierowany do swojego regionu, chyba że niedostępny), conflict resolution dla jednoczesnych zmian konfiguracji.

Active-active jest 2-3x droższy od active-passive (podwójna infrastruktura działająca jednocześnie + synchronizacja overhead), ale oferuje: RTO <30 sekund, RPO ~0 (synchroniczna replikacja), brak utraty sesji przy awarii jednego regionu (re-establish w <5s). Uzasadniony dla STATE przy cenie 2500€/user i wymaganiach dostępności 99.95%.

Data sync lag. Active-passive: IAM state 15 minut (STANDARD) do 1 minuty (PRO). PKI CRL: 5 minut. Config: 5 minut. Logi: 15-30 minut (niższa priorytet). Active-active: IAM state <1 sekunda (synchroniczny). PKI CRL: <1 sekunda. Config: <1 sekunda. Logi: 5 minut (async, bo nie na ścieżce krytycznej). Operator data (workload) NIE jest replikowane między regionami — zostaje w regionie per data residency policy.

110.2 Topologia ingress i egress

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 109.2, 109.5, 110.1, 110.3, 110.8

Topologia ingress/egress SYLION realizuje zasadę single point of entry, controlled egress — cały ruch wchodzi przez bramkę G1, a ruch wychodzący jest ograniczony do zdefiniowanych ścieżek. Brak shadow IT traffic, brak niekontrolowanego egress.

Ingress (G1). G1 stanowi jedyny publiczny punkt wejścia do infrastruktury SYLION w danym regionie. Cały ruch operatorski (IPsec IKEv2 z terminali) terminowany jest na G1. G1 realizuje: terminację IPsec, weryfikację certyfikatu klienta (mTLS), rate limiting (per-source IP, per-operator), DDoS mitigation (SYN cookies,

connection limits, anycast distribution), initial packet inspection (rozmiar, protokół, poprawność IKE), load balancing do węzłów G2 (per-session affinity).

Anycast dla DDoS resilience: G1 deployowany w wielu lokalizacjach (PoP) z tym samym adresem anycast IP. Ruch routowany do najbliższego PoP przez BGP. Atak DDoS obciąża tylko najbliższe PoP, a nie centralną infrastrukturę. Cleanpipe od upstream provider (OVH Anti-DDoS, Cloudflare Spectrum, Path.net) zapewnia dodatkową warstwę filtracji volumetric attacks.

Egress (kontrolowany). Ruch wychodzący z infrastruktury SYLION jest ograniczony do: (a) Egress do internetu z microVM operatorskich — przez dedykowany NAT gateway z per-tenant source IP (lub shared IP pool dla STANDARD), z logowaniem destination IP/port (bez inspekcji zawartości — Zero Trust nie przewiduje MitM na ruchu operatorskim). (b) Egress do usług zewnętrznych (CDR sources, threat intelligence feeds, OCSF responders) — przez dedicated egress proxy z whitelist destinations. (c) Egress management (software updates, container image pulls) — przez dedicated management proxy z registry mirror. (d) Brak egress z HSM hosts — fizycznie izolowana sieć.

Topologia L3/L4. Ruch operatorski: Terminal → Internet → G1 (public IP anycast) → G2 (private network) → Firecracker microVM (private TAP). Ruch zarządzania: Admin VPN → Management network → Vault/K8s/Monitoring (private only). Ruch inter-zone: G2 → microVM (Strefa 3) przez private bridge, monitoring (Strefa 4) → all zones przez private network z per-zone firewall rules. Brak direct path z internetu do czegokolwiek poza G1.

110.3 Sieć tranzytowa — łączność wewnętrzna między strefami

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 110.2, 110.4, 110.5, 110.7

Komunikacja wewnętrzna pomiędzy strefami bezpieczeństwa SYLION odbywa się wyłącznie przez prywatne łącza tranzytowe — żaden ruch inter-zone nie przechodzi przez publiczny internet. Zasada ta jest normatywna i nie podlega wyjątkom.

VPC peering. W środowiskach chmurowych (AWS, GCP, Hetzner) strefy implementowane są jako osobne VPC/VNet. Komunikacja między VPC realizowana jest przez VPC peering (direct network path w infrastrukturze dostawcy) lub private transit gateway (hub-and-spoke model). VPC peering zapewnia: niską latencję (sub-ms w tym samym AZ, 1-5ms cross-AZ), brak kosztów bandwidth (w obrębie regionu, u większości dostawców), izolację od publicznego internetu, auditowalne flow logs.

Transit gateway (hub-and-spoke). Dla deploymentów z 5+ VPC (multi-zone + multi-tenant) stosowany jest transit gateway jako centralny hub routingu. Transit gateway redukuje złożoność topologiczną z $O(n^2)$ (full mesh peering) do $O(n)$ (spoke → hub). Transit gateway realizuje: centralne route tables per-zone, centralne firewall rules (Network Firewall / Cloud Armor), centralne flow logging, segmentację route domains (management, workload, monitoring — osobne route tables).

Szyfrowanie in-transit. Mimo że VPC peering zapewnia izolację od publicznego internetu, ruch wewnętrzny jest dodatkowo szyfrowany: IPsec ESP (AES-256-GCM) między zone gateways dla ruchu cross-zone, mTLS (TLS 1.3) dla API calls między komponentami, WireGuard dla management plane connectivity. Szyfrowanie in-transit chroni przed: kompromitacją infrastruktury sieciowej dostawcy, insider threat w datacenter dostawcy, sniffing na przełącznikach sieciowych. Dla tieru STATE Confidential Computing zapewnia dodatkową warstwę — nawet administrator cloud provider nie może odszyfrować ruchu w pamięci.

Reguła: brak publicznego internetu. Żaden pakiet między strefami SYLION nie jest routowany przez publiczny internet. Dotyczy to również: replikacji baz danych (private peering), transferu backupów (private endpoints do storage), monitoring data (private VPC endpoints), container image pull (private registry mirror).

Wyjątek: ruch G1 → Internet (ingress z terminali) i egress z microVM (operator internet access) — te ścieżki z natury przechodzą przez publiczny internet, ale nie są ruchem inter-zone.

110.4 Synchronizacja inter-region

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 110.1, 110.5, 111.4, 111.5

Synchronizacja inter-region definiuje, które dane są replikowane między regionami i w jakim trybie. Zasada nadrzędna: dane operatorskie pozostają w regionie (data residency), podczas gdy dane zarządzania i bezpieczeństwa są replikowane dla zapewnienia ciągłości.

Co jest synchronizowane:

Dane	Tryb	RPO	Uzasadnienie
IAM state (użytkownicy, role, sesje)	Sync (STATE) / Near-sync (PRO)	<1s / <1min	Auth musi działać w obu regionach
PKI CRL/OCSP state	Near-sync	<5min	Odwołane certyfikaty muszą być widoczne globalnie
Config (policies, ACL)	Near-sync	<5min	Spójność polityk bezpieczeństwa
HSM key metadata	Sync	<1s	Key availability dla failover
Monitoring metrics	Async	<15min	Centralne dashboardsy, nie na ścieżce krytycznej
Audit logs (copy)	Async	<30min	Compliance — primary copy w regionie, secondary copy centralna
Backup metadata	Async	<1h	Inventory backupów

Co NIE jest synchronizowane:

Dane	Powód
Workload operatorski (pliki, sesje, dane)	Data residency — dane zostają w regionie klienta
Session content (streamed audio/video)	Ephemeral, nie podlega replikacji
Firecracker microVM state	Ephemeral, nie podlega replikacji (recreation on failover)
CDR temporary files	Przetwarzane i usuwane lokalnie
HSM private keys	Nigdy nie opuszczają HSM — replikacja przez HSM cluster replication (osobny kanał)

Mechanizmy synchronizacji. IAM: PostgreSQL logical replication (STANDARD/PRO) lub Raft-based consensus (STATE). PKI: custom CRL/OCSP propagation over mTLS API. Config: etcd cross-cluster sync (ArgoCD ApplicationSet). HSM: vendor-specific replication (Thales KeySecure, Entrust nShield) z dedykowanym, szyfrowanym kanałem. Monitoring: Thanos sidecar → Thanos query (cross-cluster). Logi: Loki shipper → centralny Loki cluster.

Conflict resolution. Dla danych synchronizowanych synchronicznie (IAM STATE): Raft consensus — leader region rozstrzyga konflikty. Dla danych near-sync: last-writer-wins z timestamp UTC (dopuszczalne, bo zmiany konfiguracji są rzadkie i zwykle sekwencyjne). Dla async: no conflict — append-only (logi, metryki) lub full sync (backup metadata).

110.5 Separacja regionów suwerennych

Status: [N] Normatywny Odbiorca: Infra | Architekt | Compliance | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 110.1, 110.4, 109.8, 114.4, 114.5, 119.2

Regiony suwerenne (sovereign regions) zapewniają pełną izolację sieciową, kryptograficzną i operacyjną dla tenantów wymagających data residency w określonej jurysdykcji. Separacja sovereign region jest normatywna dla deploymentów STATE, w których klient wymaga gwarancji, że dane nigdy nie opuszczają danej jurysdykcji.

Definicja sovereign region. Region suwerenny to izolowany segment infrastruktury SYLION, który: (a) jest fizycznie zlokalizowany w jednej jurysdykcji prawnej (np. Szwajcaria, Polska, Niemcy), (b) nie ma żadnego połączenia sieciowego z innymi regionami SYLION (fizycznie lub logicznie), (c) posiada własne klucze kryptograficzne (HSM w tej samej jurysdykcji), (d) jest zarządzany przez personel z odpowiednim statusem prawnym w danej jurysdykcji (np. obywatelstwo, poświadczenie bezpieczeństwa), (e) podlega wyłącznie prawu danej jurysdykcji.

Architektura izolacji. Sovereign region jest niezależnym deploymentem SYLION: własny management cluster, własne G1/G2, własne HSM, własny monitoring, własny Vault, własny PKI hierarchy (dedykowany Root CA lub Intermediate CA). Brak VPC peering, transit gateway, czy jakiegokolwiek połączenia sieciowego z innymi regionami. Jedynym „mostem” jest: (a) aktualizacje oprogramowania dostarczane offline (signed artifacts na zaszyfowanym nośniku), (b) compliance reporting eksportowany manualnie (zaszyfowany, podpisany raport), (c) licencjonowanie (offline license verification, nie phone-home).

Co to oznacza operacyjnie. Sovereign region nie może korzystać z centralnego management cluster. Nie może synchronizować IAM z innymi regionami. Nie może korzystać z centralnego monitoringu. Każdy sovereign region to de facto niezależna instancja SYLION z pełnym stosem zarządzania. Koszty infrastrukturalne sovereign region są 3-5x wyższe niż region standardowy (duplikacja całego stacku management). Uzasadnione wyłącznie dla klientów STATE z wymaganiami data sovereignty (np. ministerstwa, agencje wywiadowcze, instytucje bankowe podlegające krajowym regulatorom).

Przypadek: dwóch klientów STATE w różnych jurysdykcjach. Klient A (Szwajcaria) i klient B (Polska) — wymagane dwa sovereign regions, zero łączności między nimi. Management SYLION ma dostęp do obu przez osobne VPN connections, z osobnymi credentials, osobnymi audit trails. Personel z dostępem do sovereign region Polska nie ma automatycznie dostępu do sovereign region Szwajcaria i odwrotnie.

110.6 Route failover — mechanizmy przełączania ruchu

Status: [R] Rekomendowany Odbiorca: Infra | Architekt | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 110.1, 110.2, 110.8, 110.9

Mechanizmy failover routingu zapewniają ciągłość dostępu do infrastruktury SYLION w przypadku awarii pojedynczego węzła, łącza lub regionu. SYLION stosuje wielowarstwowy model failover, od poziomu BGP (najbardziej fundamentalny) po DNS-based (najwyższy poziom).

BGP-based failover. Bramki G1 anonsują prefiks anycast przez BGP do upstream providerów. W przypadku awarii G1 w jednej lokalizacji, BGP withdrawa (cofnięcie anonsu) powoduje automatyczne przekierowanie ruchu do następnej najbliższej lokalizacji G1. Czas failover: 30-90 sekund (zależny od BGP convergence time upstream providerów). BGP failover jest transparentny dla operatorów — sesje IPsec muszą być re-established (IKE_SA_INIT), ale re-keying jest automatyczny. Dla obsługi BGP wymagana jest relacja z dostawcami (AS number, IP prefix allocation, BGP session z minimum dwoma upstream providerami).

Health check-based failover. Niezależnie od BGP, health check system monitoruje dostępność G1/G2 na trzech poziomach: (a) L3 — ping/ICMP reachability, (b) L4 — TCP connection to IKE port (500/UDP, 4500/UDP), (c) L7 — IKE_SA_INIT handshake test. Health check wykonywany z minimum 3 lokalizacji, co 10 sekund. Failure threshold: 3 kolejne failures = node marked unhealthy. Health check triggers: BGP withdrawa (jeśli BGP-based), DNS record update (jeśli DNS-based), load balancer backend removal.

DNS-based failover. Backup mechanizm dla sytuacji, gdy BGP failover jest niedostępny (np. deployment bez własnego AS). DNS failover polega na: krótkim TTL (30-60s) na rekordach A/AAAA G1, monitoring-driven DNS update (zmiana rekordu na secondary IP w przypadku failure primary). DNS-based failover jest wolniejszy (zależny od TTL propagation + client cache) — target 60-120 sekund. Stosowany jako second-layer lub dla mniejszych deploymentów.

Failover hierarchy: (1) BGP anycast withdrawa (<90s), (2) Load balancer backend removal (<10s w obrębie regionu), (3) DNS record update (<120s cross-region), (4) Manual failover (break-glass, gdy automatyka zawodzi). Automatyczny failover powinien być testowany co miesiąc (chaos engineering) i dokumentowany w playbooku (126.3).

110.7 Architektura DNS

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 110.2, 110.6, 110.8

DNS w architekturze SYLION musi zapewniać bezpieczeństwo, prywatność i odporność na ataki — DNS jest historycznie jednym z najczęściej wykorzystywanych wektorów inwigilacji (DNS queries ujawniają, do jakich usług łączy się operator) i ataków (DNS spoofing, cache poisoning).

Wewnętrzny DNS per strefa. Każda strefa bezpieczeństwa posiada dedykowany resolver DNS obsługujący wyłącznie rekordy tej strefy i stref, z którymi strefa komunikuje się legitymicznie. Strefa 3 (workloady) rozwiązuje wyłącznie: nazwy G2 (upstream), nazwy usług Strefy 4 (monitoring, CDR endpoint), nazwy wewnętrzne microVM (peer discovery). Strefa 5 (management) rozwiązuje wszystkie strefy. Brak cross-zone DNS leakage — workload w Strefie 3 nie może rozwiązać nazwy management node w Strefie 5.

Split-horizon DNS. Dla komponentów dostępnych zarówno wewnętrznie, jak i zewnętrznie (np. G1 API) stosowany jest split-horizon: zewnętrzny DNS zwraca publiczny anycast IP G1, wewnętrzny DNS zwraca prywatny IP w sieci VPC. Eliminuje to hairpinning (ruch wewnętrzny wychodzący na internet i wracający do tej samej infrastruktury), redukuje latencję i zapobiega ujawnianiu wewnętrznej topologii w zewnętrznych odpowiedziach DNS.

DNSSEC. Wszystkie zewnętrzne domeny SYLION muszą mieć włączone DNSSEC (RRSIG, DNSKEY, DS records). DNSSEC chroni przed: cache poisoning (atakujący podmienia odpowiedź DNS), man-in-the-middle na DNS (przekierowanie ruchu), domain hijacking. Wewnętrzne DNS zones również powinny być podpisane DNSSEC (defense in depth), choć ryzyko jest niższe w sieci prywatnej.

DNS over HTTPS/TLS (DoH/DoT). Terminale operatorskie (Strefa 0) muszą kierować zapytania DNS przez zaszyfrowany kanał — albo przez tunel VPN (wszystkie DNS queries przez IPsec tunel do wewnętrznego resolvera), albo przez DoH/DoT do dedykowanego resolvera SYLION. Celem jest uniemożliwienie ISP operatora obserwacji, do jakich domen operatorski terminal wysyła zapytania. Router GL-iNet (Strefa 1) konfigurowany jest z DNS over TLS do wewnętrznego resolvera SYLION jako default — żadne zapytania DNS nie wychodzą do publicznych resolverów.

Zapobieganie DNS leakage. Firewall na routerze GL-iNet blokuje ruch DNS (port 53 UDP/TCP) do wszystkich serwerów poza skonfigurowanym resolverem SYLION. GrapheneOS na Pixel konfigurowany jest z Private DNS (DoT) do resolvera SYLION. Wewnętrzne firewall rules blokują DNS egress z microVM do publicznych resolverów — wyłącznie wewnętrzny resolver strefy.

110.8 Wzorce ukrytej infrastruktury

Status: [O] Opcjonalny Odbiorca: Infra | Architekt | SOC Wpływ na baseline: Średni Powiązane rozdziały: 110.2, 110.6, 110.7, 123.7, 124.3

Wzorce ukrytej infrastruktury (hidden infrastructure patterns) mają na celu utrudnienie identyfikacji i atrybuowania infrastruktury SYLION przez adversary. Są opcjonalne, ale rekomendowane dla klientów z podwyższonym profilem zagrożeń (dziennikarze, opozycja polityczna, NGO w krajach autorytarnych).

G1 bez publicznej atrybucji. G1 deployowany na adresach IP niezwiązanych publicznie z SYLION: (a) IP z puli dostawcy VPS bez reverse DNS wskazującego na SYLION, (b) brak rekordów whois łączących IP z domenami SYLION, (c) brak certyfikatów TLS z nazwą SYLION na publicznych portach (IPsec IKEv2 nie wymaga certyfikatu z nazwą domeny — certyfikat klienta jest prywatny). Cel: skanowanie IP przez adversary nie ujawnia, że dany adres jest infrastrukturą SYLION.

DDoS-resistant ingress. Oprócz anycast (110.6), stosowane są: (a) IP rotation — okresowa zmiana publicznych adresów G1 (co 7-30 dni) z aktualizacją konfiguracji klientów przez secure channel, (b) port knocking lub single packet authorization (SPA) — fwknop — G1 nie odpowiada na żadne pakiety, dopóki nie otrzyma poprawnego SPA packet, co czyni G1 „niewidocznym” dla skanerów. (c) Tarpit/deception — G1 odpowiada na nieautoryzowane połączenia z fałszywymi bannerami (np. HTTP 200 z generyczną stroną), utrudniając fingerprinting.

IP rotation strategies. Dla klientów z aktywnym adversary (state-level threat model) IP G1 może być rotowane: (a) proaktywnie (co 7-30 dni) — nowy IP, stary wygasza się po 48h, (b) reaktywnie (po wykryciu scan/probe) — natychmiastowe przeniesienie na nowy IP, (c) per-operator (każdy operator otrzymuje inny endpoint IP) — kompromitacja IP jednego operatora nie ujawnia IP innych. IP rotation wymaga mechanizmu bezpiecznej dystrybucji nowego endpointu do terminali (push przez istniejący tunel lub out-of-band channel).

Ograniczenia. Hidden infrastructure nie chroni przed: analizą ruchu na poziomie ISP (ISP widzi, że terminal łączy się z IP, nawet jeśli nie wie, że to SYLION), kompromitacją terminala (terminal ma adres G1 w konfiguracji), wydaniem sądowym wobec dostawcy IP (dostawca zna tożsamość klienta, który wynajmuje IP).

110.9 Ewakuacja regionu

Status: [R] Rekomendowany Odbiorca: Infra | Architekt | SOC | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 110.1, 110.4, 110.6, 111.5, 126.4

Ewakuacja regionu (region evacuation) to procedura planowego lub awaryjnego przeniesienia workloadów i danych z regionu, który staje się niedostępny, niebezpieczny lub prawnie problematyczny. Scenariusze obejmują: katastrofę naturalną, zmianę prawną w jurysdykcji regionu, kompromitację infrastruktury, sankcje lub embargo, wypowiedzenie umowy z dostawcą.

Kiedy ewakuować. Decyzja o ewakuacji regionu jest decyzją executive-level (CEO/CTO/CISO). Automatyczny failover (110.1) obsługuje tymczasowe awarie — ewakuacja jest permanentnym przeniesieniem. Triggery: (a) dostawca infrastruktury ogłasza zamknięcie regionu (>90 dni notice), (b) zmiana prawna nakazująca backdoor lub mandatory access (np. nowe prawo o lawful interception incompatible z modelem Zero Trust), (c) kompromitacja regionu na poziomie, który uniemożliwia remediation (rootkit w hypervisor, fizyczny dostęp adversary do serwerowni), (d) sankcje zabraniające świadczenia usług w danej jurysdykcji.

Procedura ewakuacji. (1) Decyzja i komunikacja — executive approval, notyfikacja dotkniętych klientów w ciągu 24h, wskazanie regionu docelowego. (2) Backup validation — weryfikacja kompletności backupów w regionie docelowym (lub emergency backup transfer). (3) DNS/BGP migration — przekierowanie ruchu do regionu docelowego. (4) Provisioning w regionie docelowym — deployment infrastruktury (z IaC — Terraform apply dla nowego regionu). (5) Data migration — transfer danych klientów, którzy wyrazili zgodę na zmianę regionu (data residency wymaga explicit consent). (6) Decommission starego regionu — secure wipe, key destruction, audit trail.

Notyfikacja operatorów. Operatorzy muszą zostać powiadomieni: in-app notification (banner w sesji), email do administratora klienta, secure channel (Matrix room per-tenant). Notyfikacja musi zawierać: powód ewakuacji, planowany harmonogram, wpływ na usługę (downtime), region docelowy, wymagane działania ze strony klienta (akceptacja nowego regionu).

Data consistency. Ewakuacja planowa (>7 dni notice): pełna synchronizacja danych, zero data loss. Ewakuacja awaryjna (<24h): dane z ostatniego backupu (RPO zależne od tieru — patrz 110.1), potencjalna utrata danych od ostatniego backup do momentu awarii. Dla sovereign regions ewakuacja jest szczególnie złożona — wymaga nowego sovereign region w innej jurysdykcji akceptowalnej dla klienta, co może wymagać tygodni przygotowań.

Rozdział 111. Storage, bazy danych i replikacja

111.1 Klasy storage — hot, warm, cold

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 111.2, 111.5, 111.6, 111.9, 112.1

System SYLION klasyfikuje storage w trzech warstwach termicznych odpowiadających częstotliwości dostępu, wymaganiom latencyjnym i kosztom. Klasyfikacja determinuje wybór technologii, politykę replikacji oraz retencję danych.

Hot storage (operacyjny). Dane aktywnie używane w czasie rzeczywistym: aktywne sesje operatorskie, bieżący stan IAM, aktywne polityki, cache sesji, bieżące metryki. Wymagania: latencja <1ms (read), <5ms (write), IOPS >10K per node, dostępność 99.95%. Technologie: NVMe SSD (bare-metal), io2/gp3 EBS (AWS), local SSD (GCP), NVMe storage (Hetzner). Hot storage musi być szyfrowany at rest (AES-256-GCM per-tenant key z HSM) i replikowany synchronicznie w obrębie regionu (minimum 2 repliki). Hot storage stanowi ~15-20% całkowitego storage SYLION i generuje ~60-70% kosztów storage.

Warm storage (bieżące logi i backupy). Dane wymagające dostępu w ciągu sekund-minut: logi z ostatnich 7-30 dni, codzienne backupy, metryki historyczne (30 dni), raporty compliance w trakcie generowania, tymczasowe dane CDR. Wymagania: latencja <100ms (read), IOPS >1K per node, dostępność 99.9%. Technologie:

standard SSD (gp3 EBS, standard persistent disk), object storage z acceleration (S3 Standard, GCS Standard). Warm storage szyfrowany identycznie jak hot (per-tenant keys). Replikacja asynchroniczna, cross-AZ. Warm storage stanowi ~30-40% całkowitego storage.

Cold storage (archiwum). Dane wymagające dostępu rzadko (raporty audytowe, stare logi, long-term backupy): logi >30 dni do retencji max (2 lata compliance, 5 lat STATE), backupy miesięczne i roczne, forensic evidence packages, archiwalne konfiguracje. Wymagania: latencja <1h (retrieval time dopuszczalny), koszt <0.01€/GB/miesiąc, immutability (WORM — Write Once Read Many). Technologie: S3 Glacier/Glacier Deep Archive, GCS Coldline/Archive, Hetzner Storage Box. Cold storage musi być immutable (object lock, WORM compliance mode) dla danych compliance — zapobieganie modyfikacji lub usunięciu przez kogokolwiek, włącznie z administratorami. Cold storage stanowi ~40-50% wolumenu, ale <10% kosztów storage.

Auto-tiering. Dane automatycznie migrują między warstwami na podstawie polityk retencji: hot → warm po zakończeniu sesji/dnia, warm → cold po upływie retencji cieplej (7-30 dni), cold → deletion po upływie retencji compliance (2-7 lat). Polityki auto-tieringu definiowane w Terraform, per-data-type, per-tenant (klienci STATE mogą mieć custom retention).

111.2 Block vs object vs ephemeral

Status: [N] Normatywny Odbiorca: Infra | Architekt | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 109.3, 111.1, 111.6, 111.9

Wybór typu storage w SYLION determinowany jest przez charakter danych i wymagania dostępowe komponentu. Trzy typy storage — block, object, ephemeral — mają wyraźnie rozgraniczone zastosowania.

Block storage. Block storage zapewnia niskolatencyjny, losowy dostęp do danych i jest wymagany dla: (a) rootfs Firecracker microVM — obraz bazowy systemu (read-only base + read-write overlay), wymagający szybkiego boot (<150ms) i I/O wydajności dla operacji systemowych; (b) PostgreSQL data directory — bazy danych IAM, konfiguracji, audytu wymagają ACID compliance, co wymaga bezpośredniego dostępu blokowego; (c) Vault storage backend — gdy Vault używa Raft storage (not Consul), wymaga niskolatencyjnego storage z IOPS guarantee; (d) Etcd — Kubernetes state store, wymagający <10ms p99 write latency.

Block storage w SYLION musi być: zaszyfrowany per-volume (dm-crypt/LUKS z kluczem z HSM), z IOPS guarantee (provisioned IOPS, nie burst-only), z snapshot capability (dla backupów), z replikacją w obrębie AZ (minimum). Dla microVM rootfs stosowany jest model: base image (read-only, współdzielony przez wszystkie microVM tego samego typu) + overlay (read-write, per-microVM, ephemeral lub persistent zależnie od polityki).

Object storage. Object storage (S3-compatible) jest wymagany dla danych bezstanowych, gdzie latencja >10ms jest akceptowalna: (a) logi — audit logs, security logs, access logs; (b) backupy — database dumps, configuration snapshots; (c) CDR staging — pliki wejściowe i wyjściowe pipeline CDR; (d) artefakty CI/CD — build artefakty, signed images; (e) compliance evidence — raporty, eksporty audytowe; (f) forensic evidence packages. Object storage zapewnia: immutability (S3 Object Lock), versioning, lifecycle policies (auto-tier do cold), cross-region replication (dla backupów). Szyfrowanie: SSE-KMS z per-tenant kluczami.

Ephemeral storage. Dane tymczasowe, które nie przeżywają restartu komponentu: (a) session temp data — tymczasowe pliki sesji operatorskiej w microVM (cache przeglądarki, clipboard, temp downloads); (b) CDR processing scratch — plik w trakcie dekompozycji/rekonstrukcji CDR; (c) build cache — tymczasowe artefakty buildu w CI/CD runner; (d) monitoring buffer — lokalny bufor przed wysłaniem do centralnego SIEM. Ephemeral storage implementowany jako: tmpfs (RAM-backed) dla wrażliwych danych (session), local SSD scratch dla mniej wrażliwych. Ephemeral storage jest niszczone automatycznie przy zakończeniu procesu/sesji — brak persistence, brak backupu, brak replikacji. Dla microVM ephemeral overlay oznacza, że po zakończeniu sesji operatorskiej wszystkie dane sesji są fizycznie usuwane (zero-fill + destroy overlay file).

111.3 Role baz danych

Status: [N] Normatywny Odbiorca: Infra | Architekt | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 111.1, 111.2, 111.4, 111.6

Architektura danych SYLION stosuje polyglot persistence — różne typy baz danych dla różnych profili danych. Brak jednej centralnej bazy „od wszystkiego” — każdy komponent korzysta z bazy optymalnej dla swojego wzorca dostępu.

PostgreSQL — dane relacyjne i transakcyjne. PostgreSQL jest primary database SYLION dla: (a) IAM — użytkownicy, role, uprawnienia, sesje, tokeny. Dane wymagające ACID, relacji (user → roles → permissions), complex queries (audit: „kto miał dostęp do zasobu X w okresie Y”). (b) Configuration — polityki bezpieczeństwa, ACL, definicje tenantów, routing rules. (c) Audit metadata — indeks logów audytowych z referencjami do szczegółów w object storage. (d) Billing/licensing — dane rozliczeniowe, subskrypcje, usage counters.

PostgreSQL deployment: HA cluster (Patroni + etcd), synchronous replication w obrębie regionu, async do secondary regionu. Connection pooling przez PgBouncer. Per-tenant logical databases (schema-per-tenant lub database-per-tenant zależnie od tieru). Row Level Security (RLS) jako dodatkowa warstwa izolacji — nawet jeśli application bug pominie tenant filter, RLS na poziomie DB zapobiega cross-tenant data access.

Time-series database — metryki i telemetria. VictoriaMetrics lub Prometheus + Thanos dla: metryk infrastruktury (CPU, RAM, network, IOPS per-component), metryk aplikacyjnych (session count, latency, error rate), metryk bezpieczeństwa (failed auth attempts, anomaly scores), SLA metrics (availability, response time). Time-series optimized storage (compression, downsampling) pozwala na retencję surowych danych 30 dni + downsampled 1 rok + aggregated 5 lat, przy koszcie ~5% tego, co kosztowałoby w PostgreSQL.

Document store — konfiguracje i polityki. Opcjonalnie: MongoDB lub PostgreSQL JSONB dla: policy documents (JSON/YAML policies z wersjonowaniem), playbook definitions, template storage, rich configuration objects. W praktyce PostgreSQL z kolumnami JSONB pokrywa większość przypadków, eliminując potrzebę osobnego document store — rekomendowane dla uproszczenia stacku.

In-memory cache — sesje i routing. Redis lub KeyDB dla: session state (aktywne sesje operatorskie, routing info), rate limiting counters, real-time presence (kto jest online), temporary tokens. TTL-based auto-expiry, no persistence (ephemeral data — loss is acceptable, session re-established). Redis sentinel lub cluster dla HA.

111.4 Strategia replikacji

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 110.1, 110.4, 111.1, 111.5

Replikacja danych w SYLION stosuje dwa tryby — synchroniczny i asynchroniczny — w zależności od krytyczności danych i wymagań RPO. Wybór trybu ma bezpośredni wpływ na dostępność, wydajność i koszty.

Replikacja synchroniczna. Zapis potwierdzony klientowi dopiero po zapisie na minimum dwóch replikach. Stosowana dla: (a) IAM state — utrata lub niespójność danych IAM oznacza potencjalny unauthorized access; kluczowe operacje (tworzenie użytkownika, zmiana roli, odwołanie tokenu) muszą być spójne na wszystkich replikach natychmiast. (b) Active session state — informacja o aktywnych sesjach musi być spójna dla prawidłowego routingu i policy enforcement. (c) PKI state — status certyfikatów (odwołanie) musi być natychmiast widoczny.

Replikacja synchroniczna wewnątrz regionu (cross-AZ): latencja zapisu zwiększona o ~1-3ms (akceptowalne). Cross-region synchroniczna replikacja: latencja zwiększona o ~20-100ms (zależnie od odległości geograficznej) — stosowana wyłącznie dla STATE active-active (110.1), gdzie wymaganie RPO ~0 uzasadnia koszt wydajnościowy. Implikacja: PostgreSQL z synchronous_commit = on i synchronous_standby_names ustawionym na minimum 1 standby.

Replikacja asynchroniczna. Zapis potwierdzony klientowi po zapisie na primary; repliki aktualizowane z opóźnieniem (lag). Stosowana dla: (a) Logów audytowych — logi są append-only, utrata kilku sekund logów jest akceptowalna (RPO 1-15 minut). (b) Backupów — cross-region backup replication z RPO 15-60 minut. (c) Metryk — telemetria monitoringu z RPO 5-15 minut. (d) Danych operatorskich (jeśli persistent) — workload data z RPO 15 minut (STANDARD) do 1 minuty (PRO).

RPO implikacje per tier:

Dane	STANDARD RPO	PRO RPO	STATE RPO
IAM	15 min	1 min	~0 (sync)
Session state	n/a (ephemeral)	1 min	~0 (sync)
Audit logs	30 min	15 min	5 min
Config	15 min	5 min	~0 (sync)
Operator data	15 min	5 min	1 min

Monitoring replikacji. Replication lag jest critical metric: alert na lag >10s (sync powinno być <1s), alert na lag >5 min (async powinno być <1 min w normalnych warunkach). Replication lag dashboard widoczny w SOC Grafana. Eskalacja na lag >15 minut (ryzyko utraty danych przekracza RPO STANDARD).

111.5 Topologia backupów

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 111.1, 111.4, 111.6, 112.4, 128.7

Backup jest ostatnią linią obrony przed utratą danych i musi być projektowany z założeniem, że wszystkie inne mechanizmy ochrony zawiodły (ransomware, insider sabotage, katastrofa fizyczna). SYLION stosuje rozszerzoną wersję reguły 3-2-1-1-0.

Reguła 3-2-1-1-0. (3) Minimum 3 kopie danych: production + 2 backupy. (2) Na minimum 2 różnych mediach/technologiach: block storage (production) + object storage (backup 1) + cold storage/offline (backup 2). (1) Minimum 1 kopia off-site: w innym regionie geograficznym (minimum 100km odległości). (1) Minimum 1 kopia immutable: WORM storage (S3 Object Lock compliance mode), niedostępna do modyfikacji nawet dla administratorów z pełnymi uprawnieniami — ochrona przed ransomware i insider sabotage. (0) Zero błędów w restore test: każdy backup weryfikowany automatycznie przez restore test (co najmniej raz na tydzień).

Schemat backupów:

Typ	Częstotliwość	Retencja	Lokalizacja	Immutable
Continuous WAL	Ciągły (streaming)	24h	Same region, object storage	Nie
Daily full	1x dziennie (02:00 UTC)	30 dni	Same region + cross-region	Tak (30 dni)
Weekly full	1x w tygodniu (niedziela)	12 tygodni	Cross-region	Tak (12 tygodni)
Monthly full	1x w miesiącu	24 miesiące	Cross-region + cold	Tak (24 miesiące)
Yearly archive	1x w roku	7 lat (tax) / 10 lat (STATE)	Cold + offline	Tak (pełna retencja)

Cross-region replication. Backupy daily+ replikowane do secondary regionu. Dla sovereign regions: backup replication wyłącznie w obrębie tej samej jurysdykcji (np. Szwajcaria → Szwajcaria, nie Szwajcaria → Niemcy). Replication szyfrowana end-to-end (backup zaszyfrowany per-tenant kluczem przed transferem).

Immutable backup storage. S3 Object Lock w compliance mode (nie governance mode — governance pozwala na usunięcie z root credentials, compliance nie). Retention period ustawiony na backup retention window. Nawet root/admin AWS nie może usunąć obiektu w compliance mode przed upływem retention. Alternatywnie: dedykowany backup storage z WORM firmware (Dell PowerProtect, NetBackup appliance) dla deploymentów on-premise STATE.

Restore testing. Automatyczny restore test co tydzień: (1) restore najnowszego daily backup do izolowanego środowiska, (2) verification script sprawdza spójność danych (row counts, checksums, schema validation), (3) raport wynik → compliance dashboard. Ręczny DR test co kwartał: pełny restore do secondary regionu z symulacją failover (126.4). Wynik restore test jest evidence dla audytu ISO 27001 i SOC 2.

111.6 Szyfrowanie at rest

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 111.1, 111.2, 111.5, 119.3

Wszystkie dane w spoczynku (at rest) w infrastrukturze SYLION muszą być zaszyfrowane. Brak wyjątków — dotyczy to: danych produkcyjnych, backupów, logów, metryk, artefaktów CI/CD, konfiguracji i tymczasowych plików przetwarzania.

Algorytm i klucze. Szyfrowanie AES-256-GCM (authenticated encryption) z kluczami zarządzanymi przez HSM. Hierarchia kluczy: (a) Master Key (MK) — w HSM, nigdy nie opuszcza HSM, używany wyłącznie do szyfrowania Data Encryption Keys. (b) Tenant Key (TK) — per-tenant, przechowywany w HSM, używany do szyfrowania kluczy danych tenanta. (c) Data Encryption Key (DEK) — per-volume/per-object, generowany przez HSM, szyfrowany TK, przechowywany razem z danymi (envelope encryption). Model envelope encryption oznacza, że: kompromitacja storage nie ujawnia danych (brak DEK w plaintext), kompromitacja jednego DEK nie ujawnia danych innych woluminów (key isolation), rotacja TK nie wymaga re-szyfrowania wszystkich danych (wystarczy re-wrap DEK nowym TK).

Per-tenant keys. Każdy tenant posiada dedykowany Tenant Key w HSM. Oznacza to, że: tenant A nie może odszyfrować danych tenant B nawet przy dostępie do raw storage; decommissioning tenanta = crypto shredding (usunięcie TK z HSM czyni wszystkie dane tenanta permanentnie nieodszyfrowalnymi). Crypto shredding jest

komplementarny do fizycznego usunięcia danych — spełnia wymóg GDPR right to erasure nawet jeśli dane fizycznie pozostają na storage (np. w backupach, których modyfikacja jest niemożliwa w WORM mode).

Rotacja kluczy. DEK: rotacja przy każdym nowym woluminie/obiekcie (automatyczna). TK: rotacja co 90 dni (automated key rotation w HSM). MK: rotacja co 365 dni (procedura dwuosobowa z HSM admin). Rotacja TK: nowe dane szyfrowane nowym DEK z nowym TK; stare dane zachowują stare DEK ze starym TK aż do natural expiry lub tła re-encryption.

Storage-level encryption. Oprócz application-level encryption (envelope), stosowane jest storage-level encryption jako defense-in-depth: dm-crypt/LUKS na block devices (bare-metal, VM), provider encryption (AWS EBS encryption, GCP CMEK) z kluczami SYLION (BYO-KMS). Dwie warstwy szyfrowania (application + storage) zapewniają ochronę nawet jeśli jedna warstwa zostanie obejścia (np. bug w aplikacji pomijający envelope encryption — dane nadal zaszyfrowane na warstwie storage).

111.7 Storage dla logów

Status: [N] Normatywny Odbiorca: Infra | Architekt | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 111.1, 111.5, 111.6, 116.9, 118.5

Logi stanowią kluczowy element dowodowy dla audytów, śledztw i compliance — muszą być przechowywane w sposób zapewniający integralność, dostępność i niemodyfikowalność.

WORM compatibility. Logi audytowe i bezpieczeństwa muszą być przechowywane na WORM-compatible storage. Oznacza to: (a) append-only — nowe wpisy mogą być dodawane, ale istniejące nie mogą być modyfikowane ani usuwane; (b) retention lock — minimalny okres retencji (2 lata compliance, 5 lat STATE) wymuszony na poziomie storage, nie aplikacji; (c) tamper-evident — jakkolwiek próba modyfikacji jest wykrywalna i logowana.

Hash chain verification. Logi SYLION organizowane są w łańcuchy hashowe (hash chain / append-only Merkle tree): każdy wpis logu zawiera hash poprzedniego wpisu, tworząc kryptograficzny łańcuch integralności. Modyfikacja lub usunięcie dowolnego wpisu łamie łańcuch — jest to wykrywalne przez automatyczną weryfikację integralności. Weryfikacja uruchamiana: co godzinę (automated), na żądanie (auditor request), przy eksporcie (evidence packaging). Hash algorithm: SHA-256 (NIST approved, PQC-resistant dla integrity).

BYO-KMS (Bring Your Own KMS). Klienci PRO i STATE mogą dostarczyć własne klucze szyfrujące dla swoich logów (BYO-KMS). Oznacza to, że SYLION nie może odszyfrować logów klienta bez kooperacji klienta. Klient kontroluje dostęp do swoich danych auditowych. BYO-KMS implementowany przez: klient dostarcza KMS endpoint (AWS KMS, Azure Key Vault, GCP Cloud KMS, lub on-premise HSM), SYLION szyfruje logi klienta DEK-iem opakowanym kluczem klienta, klient może odwołać klucz — uniemożliwiając SYLION dostęp do logów.

Struktura logów. Każdy wpis logu zawiera: timestamp (UTC, nanosecond precision), event_type (enum), actor (who), target (what), action (what was done), result (success/failure), source_ip (obfuscated for privacy), tenant_id, session_id (if applicable), previous_hash (hash chain), signature (log entry signed by log service key). Logi przechowywane w formacie JSON Lines (JSONL) — jeden wpis per linia, ułatwiający streaming, parsing i indexing.

111.8 Storage dla dowodów forensycznych

Status: [R] Rekomendowany Odbiorca: Infra | SOC | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 111.7, 119.5, 126.3

Storage forensyczny przechowuje pakiety dowodowe (evidence packages) tworzone podczas incydentów bezpieczeństwa lub na żądanie organów ścigania. Wymaga szczególnych gwarancji integralności i chain of custody.

Chain of custody. Każdy evidence package musi mieć udokumentowany łańcuch custody: kto stworzył pakiet (identyfikacja z certyfikatem), kiedy (timestamp z NTP-synchronized source), z jakich źródeł (referencje do logów, snapshotów, captures), kto miał dostęp (log dostępu do evidence storage), czy pakiet był modyfikowany (hash verification at each access). Chain of custody jest wymagany przez sądy i regulatorów jako warunek dopuszczalności dowodów elektronicznych.

Immutability proof. Evidence package po zamknięciu (finalization) staje się immutable: (a) hash SHA-256 pakietu zapisywany w osobnym, niezależnym systemie (second hash store — może to być blockchain-like append-only log, może to być notarization service), (b) timestamp kwalifikowany (RFC 3161 Timestamping Authority) — dowód, że pakiet istniał w danym momencie i nie był modyfikowany od tego czasu, (c) digital signature twórcy pakietu (certyfikat SOC analyst).

Access logging. Każdy dostęp do evidence storage (read, list, download) jest logowany z: identyfikacją osoby, uzasadnieniem (ticket number, court order reference), timestamp, zakresem dostępu (jakie pakiety, jakie dane). Access log evidence storage jest sam immutable (hash chain, WORM storage) — zapobiega sytuacji, w której ktoś ukrywa fakt, że przeglądał dowody.

Retencja. Evidence packages retencjonowane minimum 7 lat (dłużej niż standardowe logi), ze względu na potencjalne postępowania sądowe, które mogą trwać latami. Dla STATE: retencja 10+ lat lub „indefinite until case closed”. Cold storage z WORM (111.1) jest odpowiedni pod warunkiem, że retrieval time <24h jest akceptowalny (dla aktywnych śledztw evidence powinien być w warm storage).

111.9 Warstwy wydajności storage

Status: [R] Rekomendowany Odbiorca: Infra | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 111.1, 111.2, 112.7

Wymagania wydajnościowe storage różnią się drastycznie między komponentami SYLION. Dobranie odpowiedniego tier wydajności per komponent jest kluczowe dla wydajności i optymalizacji kosztów.

Wymagania IOPS per komponent:

Komponent	Read IOPS	Write IOPS	Latencja p99	Uwagi
PostgreSQL IAM	5-10K	2-5K	<5ms	Burst przy auth storm
Etcd (K8s)	2-5K	1-3K	<10ms	Wrażliwy na latencję zapisu
Vault Raft storage	1-3K	1-2K	<5ms	Consistent write latency critical
Firecracker rootfs	500-2K	200-500	<2ms	Boot time zależy od read latency
Redis/KeyDB	n/a (RAM)	n/a (RAM)	<1ms	In-memory, persistence secondary

Log ingestion	100-500	5-10K	<50ms	Write-heavy, sequential
Object storage	100-1K	100-500	<100ms	Throughput ważniejszy niż latency
Backup storage	<100	<100	<1s	Throughput-oriented, nie IOPS

Auto-tiering. Automatyczna migracja danych między warstwami wydajności na podstawie access patterns: dane nieodczytywane >7 dni migrowane z NVMe SSD do standard SSD, >30 dni do object storage, >90 dni do cold/archive. Auto-tiering redukuje koszty storage o 40-60% vs utrzymywanie wszystkiego na NVMe.

Latency targets per ścieżka krytyczna. Ścieżka sesji operatorskiej (auth → session establish → microVM boot → remote desktop) ma end-to-end latency target <500ms. Storage latency budget na tej ścieżce: IAM query <5ms, session state write <5ms, rootfs read (microVM boot) <50ms, overlay creation <10ms. Łączny storage contribution: <70ms, co zostawia >430ms na compute i network. Monitoring latencji storage jest częścią SLA monitoring (117.1).

Rozdział 112. Koszty, optymalizacja i FinOps

112.1 Model kosztowy per komponent

Status: [N] Normatywny Odbiorca: Infra | Architekt | Finance | Zarząd Wpływ na baseline: Wysoki Powiązane rozdziały: 109.2, 109.3, 112.2, 112.3, 112.10

Transparentność kosztowa jest fundamentem zdrowego modelu biznesowego SYLION. Każdy komponent infrastruktury ma przypisany koszt, który jest alokowany do tenantów i tierów.

Węzły G1/G2. G1 i G2 deployowane na VPS: koszt ~20-40€/miesiąc per instancja (Hetzner CX42 lub CPX41). Typowy deployment: 2x G1 (HA) + 2x G2 (HA) = 4 instancje = 80-160€/miesiąc. Koszt amortyzowany na liczbę obsługiwanych operatorów (G1/G2 HA pair obsługuje 50-200 operatorów jednocześnie).

Operator microVM VPS. 3 VPS per operator (per-operator trójka zapewniająca redundancję i izolację): 3 × 20€ = 60€/miesiąc per operator. Jest to dominujący koszt infrastruktury per-operator. VPS specyfikacja: 2 vCPU, 4GB RAM, 40GB SSD — wystarczające dla standardowego workloadu operatorskiego (remote desktop, komunikacja, przetwarzanie dokumentów).

Management zone. Klaster management (Vault, monitoring, CI/CD, orchestrator): ~300-600€/miesiąc dla małego deploymentu (3 nodes). Alokowany na operatorów: przy 50 operatorach = ~6-12€/user/miesiąc; przy 100 operatorach = ~3-6€/user/miesiąc. Bazowe założenie: ~6€/user/miesiąc (management zone allocation).

Matrix homeserver (opcjonalny). Dedykowany Synapse homeserver per tenant: ~20€/miesiąc (VPS + storage). Opcjonalny — klienci mogą korzystać z wbudowanego systemu komunikacji lub własnego Matrix homeserver.

SIEM/monitoring. Prometheus + Grafana + Loki stack: ~50-100€/miesiąc (infrastruktura). Alokowane na operatorów. Przy 50 użytkownikach: ~1-2€/user/miesiąc.

HSM. Cloud HSM (AWS CloudHSM): ~1,500\$/miesiąc per instancja. On-premise HSM (Thales Luna): ~5-15K€/rok amortyzacja zakupu + maintenance. HSM alokowane na tenantów: shared partition (STANDARD/PRO), dedicated partition lub dedicated HSM (STATE).

Bandwidth. IPsec traffic: ~1-5TB/miesiąc per operator (remote desktop + komunikacja). Koszt: ~0.01-0.05€/GB (zależnie od dostawcy) = ~10-250€/miesiąc per operator. W praktyce wielu dostawców (Hetzner) oferuje generous bandwidth included, redukując ten koszt do ~0.

112.2 Model kosztowy per tenant

Status: [N] Normatywny Odbiorca: Finance | Zarząd | Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 112.1, 112.3, 112.9

Pełny stos kosztów per operator pozwala na kalkulację marży i ocenę rentowności na poziomie pojedynczego klienta.

Kalkulacja STANDARD (per operator/miesiąc):

Pozycja	Koszt
3 × VPS (workload)	60€
Management zone allocation	6€
G1/G2 allocation (1/50 share)	3€
Monitoring allocation	2€
HSM allocation (shared)	1€
Bandwidth	0-5€
Infrastruktura razem	~72-77€
Wsparcie techniczne (allocated)	10-20€
Utrzymanie/rozwój (allocated)	15-30€
Koszt pełny razem	~97-127€

Cena STANDARD: 400€/user/miesiąc (przy subskrypcji rocznej: 400€ × 12 / 12 = 400€/mies, przy półrocznej wyższa efektywna cena). Marża brutto infrastruktura: (400 - 77) / 400 ≈ 80-81%. Marża po uwzględnieniu kosztów ludzkich: (400 - 127) / 400 ≈ 68-76%.

Kalkulacja z opcjonalnym Matrix:

Pozycja	Koszt
Infrastruktura bazowa	72-77€
Matrix homeserver allocation	20€
Infrastruktura razem z Matrix	~92-97€

Marża brutto z Matrix: $(400 - 97) / 400 \approx 76\%$. Nadal zdrowa marża — Matrix jest opcjonalny ale nie wpływa istotnie na rentowność.

Breakeven per operator. Minimalna cena dla pokrycia kosztów infrastruktury: ~77€/miesiąc. Z kosztami ludzkimi: ~127€/miesiąc. Cena 400€ zapewnia zdrowy bufor na: (a) nieprzewidziane koszty (security incidents, emergency scaling), (b) inwestycje w rozwój (PQC, certyfikacje), (c) marketing i sprzedaż (CAC), (d) marżę operacyjną spółki.

Efekt skali. Koszty management zone, G1/G2, monitoring, HSM są w dużej mierze stałe (fixed). Im więcej operatorów, tym niższe alokowane koszty per operator. Przy 100 operatorach management allocation spada do ~3€/user, monitoring do ~1€/user. Efektywna marża brutto infra rośnie do ~85% przy 100+ operatorach.

112.3 Model kosztowy per tier

Status: [N] Normatywny Odbiorca: Finance | Zarząd Wpływ na baseline: Wysoki Powiązane rozdziały: 112.1, 112.2, 112.4

Każdy tier usługi ma odmienny profil kosztowy i marżowy, wynikający z różnic w infrastrukturze, poziomie wsparcia i wymaganiach compliance.

STANDARD (400€/user/miesiąc, subskrypcja 6 lub 12 miesięcy): - Infrastruktura: ~72-77€/user/miesiąc - Koszty operacyjne (human): ~50€/user/miesiąc (amortyzacja wsparcia, rozwoju, operacji) - Łączny koszt: ~127€/user/miesiąc - Marża brutto: ~81% (infra only), ~68% (pełna) - Profil: wysoki wolumen, niska customizacja, efekt skali na management costs

PRO (1500€/user/miesiąc, subskrypcja 12 miesięcy): - Infrastruktura: ~100-120€/user/miesiąc (wyższe IOPS, namespace isolation, dedykowana HSM partition) - Koszty operacyjne: ~80-100€/user/miesiąc (dedykowane wsparcie, SLA management) - Łączny koszt: ~180-220€/user/miesiąc - Marża brutto: ~92% (infra), ~85-88% (pełna) - Profil: średni wolumen, umiarkowana customizacja, premium support

STATE (2500€/user/miesiąc, min 50 users, 12 miesięcy): - Infrastruktura: ~200-350€/user/miesiąc (dedykowany cluster, bare-metal HSM, multi-region, Confidential Computing) - Koszty operacyjne: ~150-250€/user/miesiąc (dedicated SOC, professional deployment, on-site training, compliance management) - Professional services (amortyzowane): ~50-100€/user/miesiąc (initial deployment, customization) - Łączny koszt: ~400-700€/user/miesiąc - Marża brutto: ~86-90% (infra), ~72-84% (pełna) - Profil: niski wolumen, wysoka customizacja, highest touch

Marża porównawcza:

Tier	Cena	Koszt pełny	Marża pełna
STANDARD	400€	~127€	~68%
PRO	1500€	~200€	~87%
STATE	2500€+	~550€	~78%

PRO oferuje najwyższą marżę procentową, ponieważ koszty infrastruktury rosną wolniej niż cena, a customization jest umiarkowana. STATE ma niższą marżę procentową ale najwyższą marżę absolutną per user i gwarantuje minimum $50 \times 2500 = 125K\text{€}$ /rok per klient.

112.4 Koszt odporności

Status: [R] Rekomendowany Odbiorca: Finance | Architekt | Zarząd Wpływ na baseline: Średni Powiązane rozdziały: 110.1, 111.5, 112.1, 112.3

Odporność (resilience) — wysoka dostępność i disaster recovery — ma wymierny koszt infrastruktury. Decyzja o poziomie odporności musi balansować koszt vs ryzyko biznesowe.

High Availability (HA) — +20% kosztów infrastruktury. HA wymaga duplikacji komponentów krytycznych w obrębie regionu: 2x G1, 2x G2, 3x Kubernetes control plane nodes, 2x PostgreSQL (primary + sync standby), 2x Vault (active + standby), 2x Redis sentinel. Dodatkowy koszt: ~20% bazy infrastruktury (nie 100%, bo nie wszystko wymaga duplikacji — storage jest współdzielony, compute nodes są dodatkowe ale obsługują workloady).

Efekt na SLA: single region HA zapewnia 99.95% availability (target STANDARD/PRO). Bez HA: 99.5-99.9% (single points of failure).

Multi-region — +80% kosztów infrastruktury. Multi-region (active-passive) wymaga: pełna infrastruktura w secondary regionie (G1/G2, compute, storage, monitoring), cross-region replication (bandwidth + storage), management overhead (monitoring obu regionów). Dodatkowy koszt: ~80% bazy infrastruktury (secondary region jest ~60% kosztu primary, bo workloady nie działają aktywnie, + 20% replication overhead).

Efekt na SLA: multi-region active-passive: 99.95% availability (target STATE). Multi-region active-active: 99.995%+.

Analiza per tier:

Tier	Cena/user	Infra base	+HA (20%)	+Multi-region (80%)	Sens ekonomiczny
STANDARD	400€	77€	+15€ = 92€	+62€ = 154€	HA: tak; Multi-region: nieuzasadniony kosztowo
PRO	1500€	110€	+22€ = 132€	+88€ = 220€	HA + multi-region: tak
STATE	2500€+	275€	+55€ = 330€	+220€ = 550€	HA + multi-region + active-active: tak

Rekomendacja. STANDARD: HA obowiązkowy, multi-region opcjonalny (za dopłatą). PRO: HA + multi-region active-passive w cenie. STATE: HA + multi-region active-active w cenie. Koszt odporności jest uwzględniony w modelu kosztowym per tier (112.3) i nie wymaga osobnej opłaty — jest wliczony w cenę tieru.

112.5 Koszt kontroli bezpieczeństwa

Status: [R] Rekomendowany Odbiorca: Finance | CISO | Zarząd Wpływ na baseline: Wysoki Powiązane rozdziały: 112.1, 116.1–116.10, 118.8

Kontrole bezpieczeństwa generują istotne koszty, które muszą być planowane i alokowane. Brak budżetu na bezpieczeństwo prowadzi do skróć, które zwiększają ryzyko.

HSM (€5-15K/rok). Cloud HSM (AWS CloudHSM): ~1,500/rok per instancja. On-premise HSM (Thales Luna Network HSM): ~30-50K€ zakup + ~5-8K€/rok maintenance = amortyzacja ~10-15K€/rok. Minimum 2 HSM (HA) = 10-30K€/rok. Alokacja: STANDARD (shared, koszt minimalizowany), PRO (dedicated partition,

~2-3K€/rok per tenant), STATE (dedicated HSM, ~15K€/rok per tenant).

Testy penetracyjne (€20-50K/rok). Minimum raz w roku, rekomendowane dwukrotnie. Scope: external pentest (infrastruktura), internal pentest (lateral movement), application pentest (API, web, mobile). Koszt zależny od scope: basic (external only) ~10-15K€, comprehensive (external + internal + app) ~25-40K€, red team engagement ~40-80K€. Alokacja: koszt stały, amortyzowany na wszystkich tenantów.

Audyty compliance (€30-80K/rok). ISO 27001 certification audit: ~15-25K€ (initial), ~10-15K€/rok (surveillance). SOC 2 Type II: ~30-50K€/rok (audit firm fees). FIPS 140-3 validation: ~50-100K€ jednorazowo + ~10-20K€/rok maintenance. Common Criteria EAL4+: ~200-400K€ (pełna ewaluacja). FedRAMP: ~500K-1M€ (pełna autoryzacja). Alokacja: koszty certyfikacji front-loaded (Year 1-3 highest), spadają do maintenance po certyfikacji.

Security tooling (€20-40K/rok). SIEM licensing (jeśli komercyjny), vulnerability scanner (Nessus, Qualys ~10-20K€/rok), code scanning (SAST/DAST ~5-15K€/rok), secret scanner, dependency scanner. Wiele narzędzi open-source (Prometheus, Trivy, gitleaks) redukuje ten koszt.

Alokacja na tenantów. Koszty bezpieczeństwa alokowane proporcjonalnie do przychodu per tier: STATE płaci więcej za dedykowane kontrole, STANDARD korzysta z ekonomii skali. Łączny security overhead: ~5-10% przychodu, co jest w normie branżowej dla enterprise security products.

112.6 Planowanie pojemności

Status: [R] Rekomendowany Odbiorca: Infra | Finance Wpływ na baseline: Wysoki Powiązane rozdziały: 109.3, 109.8, 112.7, 112.8

Planowanie pojemności zapewnia, że infrastruktura SYLION ma wystarczające zasoby do obsługi bieżących i przyszłych workloadów bez over-provisioning (marnowanie pieniędzy) lub under-provisioning (degradacja wydajności/dostępności).

Operatorzy per node. Host Firecracker (8 vCPU, 32GB RAM): ~30-50 microVM jednocześnie (przy 256MB-512MB RAM per microVM). Host Firecracker (16 vCPU, 64GB RAM): ~80-120 microVM. Host Firecracker (32 vCPU, 128GB RAM): ~200+ microVM. Ratio: ~4 microVM per vCPU, ~60 microVM per 1GB RAM overhead. Actual capacity zależy od workload profile — remote desktop jest bardziej CPU-intensive niż komunikacja tekstowa.

Scaling triggers. Automatyczne skalowanie uruchamiane przez: (a) CPU utilization hosta >70% sustained (15 min) → dodaj node, (b) RAM utilization >80% → dodaj node, (c) microVM queue (operatorzy czekający na provisioning) >5 → dodaj node, (d) session latency p95 >200ms → investigate + possibly scale. Down-scaling: CPU <30% sustained 1h AND no pending microVM requests → remove node (po draining active sessions).

Burst capacity. Pojemność burst dla nagłego wzrostu zapotrzebowania: (a) pre-warmed pool — 10-20% dodatkowych zasobów utrzymywanych jako „gorąca rezerwa”, ready do natychmiastowego provisioningu microVM, (b) auto-scaling z cloud provider — nowe VPS provisioned w <5 minut (Hetzner Cloud API), (c) overflow to on-demand instances (jeśli reserved capacity wyczerpana).

Pre-provisioning dla STATE. Klienci STATE mają gwarantowane zasoby: (a) dedicated nodes pre-provisioned na 100% contracted capacity, (b) burst capacity +50% na dedicated nodes, (c) brak over-subscription — STATE resources nie są współdzielone z innymi tenantami. Pre-provisioning oznacza wyższy koszt (node działa nawet gdy operator nie jest aktywny), ale gwarantuje instant availability.

112.7 Rightsizing — dobór zasobów

Status: [R] Rekomendowany Odbiorca: Infra | Finance Wpływ na baseline: Średni Powiązane rozdziały: 109.3, 112.1, 112.6

Rightsizing to proces ciągłej optymalizacji zasobów przypisanych do workloadów — przydzielanie dokładnie tyle, ile potrzeba, nie więcej, nie mniej.

MicroVM resource profiling. Monitoring zużycia zasobów per microVM: CPU utilization, RAM usage, I/O throughput, network bandwidth. Po 30 dniach danych profiling generuje recommendation: (a) oversized microVM (CPU usage <20%, RAM usage <40%) → reduce allocation, (b) undersized microVM (CPU >80%, RAM >90%, frequent OOM) → increase allocation. Default allocation: 1 vCPU, 512MB RAM, 10GB disk. Po profilingu: adjustment w zakresie 0.5-4 vCPU, 256MB-2GB RAM, 5-40GB disk.

Workload-specific sizing. Różne profile operatorów wymagają różnych zasobów: (a) komunikacja tekstowa (Matrix/chat): 0.5 vCPU, 256MB RAM, (b) remote desktop (web browsing, dokumenty): 1 vCPU, 512MB-1GB RAM, (c) programowanie/kompilacja: 2-4 vCPU, 1-2GB RAM, (d) przetwarzanie wideo/audio: 2 vCPU, 1GB RAM. Profilowanie automatyczne na podstawie wzorców użycia pozwala na dynamic sizing — microVM startuje z default allocation i jest dynamicznie resize'owana po wykryciu workload profile. Firecracker wspiera hot-plug CPU i balloon driver dla RAM — zmiana zasobów bez restartu microVM.

Idle detection. Operatorzy nieaktywni (brak interakcji >30 minut) — microVM może być: (a) suspended (CPU de-allocated, RAM preserved) — resume w <1s, (b) hibernated (CPU + RAM saved to disk) — resume w <5s, (c) terminated (after idle timeout 2h) — re-provision on next login. Idle management redukuje effective resource usage o 30-50% (nie wszyscy operatorzy aktywni jednocześnie).

112.8 Pojemność zarezerwowana vs on-demand

Status: [R] Rekomendowany Odbiorca: Infra | Finance Wpływ na baseline: Niski Powiązane rozdziały: 112.1, 112.6, 112.7

Optymalizacja kosztów compute przez strategiczny mix reserved i on-demand capacity.

Reserved capacity. Serwery/VPS zakontraktowane na 12-36 miesięcy z rabatem: Hetzner dedicated servers: ~20-30% taniej z rocznym kontraktem. AWS EC2 Reserved Instances: ~30-60% taniej (1-3 year commitment). Reserved capacity stosowana dla: base load (minimalna liczba operatorów gwarantowana kontraktem), management infrastructure (stała), G1/G2 (stała), HSM hosts (stała).

Obliczenie base load: jeśli kontrakt gwarantuje 50 operatorów, potrzebujemy ~2 host nodes (50 microVM) + management + G1/G2 = stała infrastruktura, która będzie działać 24/7/365. Koszt reserved: ~3,000€/miesiąc (50 operatorów, pełny stack). Koszt on-demand equivalent: ~4,500€/miesiąc. Oszczędność: ~33%.

On-demand capacity. Serwery/VPS dostępne natychmiast, płatne per godzina/miesiąc bez commitmentu. On-demand stosowane dla: burst (nagły wzrost ponad base load), testowanie (krótkotwałe środowiska), nowi klienci (przed commitment na reserved), DR secondary region (aktywowany rzadko).

Optymalny mix. Reserved: 70-80% anticipated base load. On-demand: 20-30% dla burst i flexibility. Overcommit on reserved: 0% (lepiej mieć lekki overhead reserved niż under-committed). Przegląd quarterly: jeśli on-demand usage >30% consistent, zwiększ reserved; jeśli reserved utilization <60%, zmniejsz reserved.

112.9 Governance FinOps

Status: [R] Rekomendowany Odbiorca: Finance | Infra | Zarząd Wpływ na baseline: Średni Powiązane rozdziały: 112.1–112.8, 112.10

FinOps (Financial Operations) to dyscyplina zarządzania kosztami chmury łącząca engineering, finance i business. W SYLION FinOps zapewnia, że koszty infrastruktury są transparentne, kontrolowalne i zoptymalizowane.

Cost visibility per tenant. Każdy zasób infrastruktury tagowany per-tenant (tenant_id, tier, region). Cost allocation engine agreguje koszty: per tenant, per tier, per component, per region. Dashboardsy kosztowe dostępne dla: Finance (pełna widoczność), CTO (koszty techniczne), Account Managers (koszty per klient). Granularność: dzienne koszty per tenant per component.

Showback/chargeback model. Showback: wewnętrzne raportowanie kosztów per-tenant bez fakturowania (informacyjne). Chargeback: alokacja kosztów do P&L per-tier lub per-client. SYLION stosuje showback do optymalizacji i chargeback do raportowania finansowego. Model chargeback: koszty bezpośrednie (VPS, bandwidth) alokowane 1:1, koszty współdzielone (management, monitoring, security) alokowane proporcjonalnie do liczby operatorów per tenant.

Anomaly detection. Automatyczne wykrywanie anomalii kosztowych: (a) daily cost spike >20% vs 7-day moving average → alert do Infra + Finance, (b) new resource provisioned outside IaC (manual) → alert + investigation, (c) orphaned resources (resources not tagged, not in use) → weekly cleanup report. Machine learning-based anomaly detection (AWS Cost Anomaly Detection lub custom) identyfikuje nietypowe wzorce wydatków (np. crypto mining na skompromitowanym VPS — objawi się jako spike CPU + bandwidth).

Budget i limity. Per-tier monthly budget z alertami: 80% budget → warning, 90% → escalation do CTO, 100% → escalation do CEO + auto-remediation (jeśli overrun spowodowany anomalią). Budget per region, per component. Approved budget overruns wymagają formalnego CR z uzasadnieniem.

112.10 Raportowanie do product i finance

Status: [R] Rekomendowany Odbiorca: Finance | Zarząd | PM Wpływ na baseline: Niski Powiązane rozdziały: 112.1–112.9

Regularne raportowanie finansowe infrastruktury zapewnia informacje decyzyjne dla zarządu, product managementu i działu finansowego.

Miesięczny raport kosztów — struktura: (1) Executive summary — łączny koszt, trend (vs poprzedni miesiąc, vs budget), marża per tier. (2) Per-tier breakdown — koszty infra, koszty ludzkie, marża brutto, marża netto, per-operator koszt, per-operator przychód. (3) Per-component breakdown — top 5 kosztów, trend, optymalizacje zrealizowane/planowane. (4) Per-region breakdown — koszt regionu, utilization, efficiency. (5) Anomalie — nietypowe wydatki, ich przyczyna, remediation. (6) Forecast — prognoza kosztów na kolejny miesiąc/kwartał na podstawie pipeline sprzedaży.

Analiza marży. Monthly margin analysis per tier: przychód (MRR) vs koszt (infrastruktura + ops). Target margin: STANDARD ≥65%, PRO ≥80%, STATE ≥70%. Red flag: marża poniżej 50% na jakimkolwiek tierze wymaga natychmiastowej analizy (pricing error, cost overrun, over-provisioning).

Investment planning. Raport identyfikuje inwestycje infrastrukturalne wymagane w kolejnych kwartałach: nowe regiony, upgrade hardware (PQC, next-gen HSM), certyfikacje (koszt infrastructure adjustment), capacity expansion (nowi klienci). Investment capex vs opex classification dla raportowania finansowego.

Rozdział 113. Terraform, Ansible i zarządzanie konfiguracją infrastruktury

113.1 Standardy Infrastructure as Code (IaC)

Status: [N] Normatywny Odbiorca: Infra | Dev | SOC | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 109.1–109.8, 113.2–113.9, 128.1, 128.2, 128.3

Infrastruktura SYLION jest zarządzana wyłącznie jako kod — żadna zmiana infrastruktury nie może być wprowadzona ręcznie (outside IaC) w środowisku produkcyjnym. Zasada ta jest normatywna i stanowi fundament powtarzalności, auditowalności i bezpieczeństwa infrastruktury.

Podział narzędzi. Terraform odpowiada za provisioning (tworzenie/modyfikacja/usuwanie zasobów infrastruktury: VPS, sieci, storage, DNS, firewall rules). Ansible odpowiada za configuration (konfiguracja systemu operacyjnego, instalacja oprogramowania, hardening, deployment aplikacji). Podział jest wyraźny: Terraform „co istnieje”, Ansible „jak jest skonfigurowane”. Oba narzędzia działają w modelu deklaratywnym (opisujemy stan docelowy, narzędzie zapewnia konwergencję).

GitOps flow. Wszystkie zmiany infrastruktury przechodzą przez Git: (1) developer tworzy branch z propozycją zmiany (terraform plan output, ansible playbook diff), (2) peer review (minimum 1 reviewer z uprawnieniami Infra), (3) automated validation (terraform validate, ansible-lint, policy checks), (4) merge do main branch, (5) CI/CD pipeline automatycznie wykonuje terraform apply i ansible-playbook, (6) post-deploy verification (smoke tests, monitoring check). Brak merge do main = brak deployment.

Immutable infrastructure. SYLION preferuje immutable infrastructure pattern: zamiast modyfikować istniejący serwer (mutable, configuration drift), tworzy się nowy serwer z pożądaną konfiguracją i zastępuje stary (blue-green lub rolling). Firecracker microVM naturalnie wspierają immutable pattern — każda sesja = nowa microVM z czystego obrazu. VM i K8s nodes: rolling update z nowym image, brak in-place patching (z wyjątkiem emergency security patches — 113.8).

Audit trail. Git history stanowi pełny audit trail zmian infrastruktury: kto zmienił (Git author + reviewer), kiedy (Git timestamp), co zmienił (Git diff), dlaczego (Git commit message + linked ticket). Terraform state changes logowane do centralnego audit log. Ansible execution logowane do SIEM. Spełnia wymagania ISO 27001 A.12.1.2 (change management) i SOC 2 CC8.1 (change management).

113.2 Struktura modułów

Status: [R] Rekomendowany Odbiorca: Infra | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 113.1, 113.3, 113.9, 128.2

Moduły Terraform i Ansible organizowane są w hierarchię trójpoziomową: platform → zone → component. Hierarchia zapewnia re-usability, testability i czytelność.

Poziom platform. Moduł najwyższego poziomu definiujący całe środowisko SYLION: regiony, sieci tranzytowe, DNS, global resources (IAM, shared HSM). Moduł platform wywołuje moduły zone dla każdej strefy bezpieczeństwa. Input: environment definition (region, tier, tenant, sizing). Output: endpoint map, monitoring targets, credentials map.

Ochrona Terraform State. Terraform state zawiera pełną mapę infrastruktury SYLION: adresy IP, konfiguracje sieciowe, identyfikatory zasobów, a potencjalnie fragmenty sekretów. Kompromitacja state = pełna wiedza o topologii systemu. Wymagania: (1) state przechowywany w encrypted S3 bucket z Object Lock

(WORM), (2) dostęp wyłącznie z management zone (bastion), (3) state locking (DynamoDB lub Terraform Cloud), (4) backup state co deploy, (5) audit log każdego terraform plan/apply, (6) state NIE zawiera sekretów inline — wszystkie sekrety z Vault/OpenBao injected at apply time, (7) osobny state per tenant (state isolation), (8) periodic state audit: weryfikacja, że state odpowiada rzeczywistości (drift detection co 6h).

Poziom zone. Moduł per-strefa bezpieczeństwa: zone-ingress (G1), zone-session (G2), zone-workload (microVM hosts), zone-shared (Kubernetes, monitoring), zone-management (Vault, PKI, orchestrator). Każdy moduł zone definiuje zasoby strefy i enforcement security policies dla tej strefy (network policies, firewall rules, encryption requirements). Input: zone-specific parameters (sizing, HA config, security profile). Output: zone endpoints, security group IDs, monitoring targets.

Poziom component. Moduł per-komponent: component-g1 (single G1 instance), component-vault (Vault node), component-postgres (PostgreSQL instance), component-firecracker-host (host for microVMs). Komponenty są re-usable i testowalne niezależnie. Input: instance-specific parameters (CPU, RAM, disk, network config). Output: instance endpoint, health check URL, log destination.

Input validation. Terraform variable validation blocks dla wszystkich parametrów: type checking, range checking (CPU 1-32, RAM 256MB-128GB), enum validation (tier: STANDARD|PRO|STATE), conditional validation (STATE requires hsm_enabled = true). Walidacja failing = plan failing = brak deploy = bezpieczeństwo.

Output contracts. Każdy moduł eksportuje zdefiniowany zestaw output variables, które stanowią kontrakt z modułami wyższego poziomu. Zmiana output = breaking change, wymaga major version bump modułu i review. Outputs: endpoint (jak się połączyć z komponentem), monitoring_target (co monitorować), log_destination (dokąd wysyłać logi), security_group_id (jak izolować sieciowo).

113.3 Zarządzanie stanem

Status: [N] Normatywny Odbiorca: Infra | Dev | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 113.1, 113.2, 113.4

Terraform state przechowuje mapowanie między deklaratywną konfiguracją a rzeczywistymi zasobami. Utrata lub kompromitacja state jest incydem bezpieczeństwa.

Remote state. Terraform state przechowywany w remote backend: S3-compatible bucket z server-side encryption (AES-256-GCM, klucz z Vault/KMS). Brak local state na maszynach deweloperów — state dostępny wyłącznie przez remote backend. Backend access kontrolowany przez IAM: read access dla CI pipeline, write access wyłącznie dla terraform apply w CI/CD (nigdy dla ludzkich użytkowników w produkcji).

State encryption. State zawiera wrażliwe dane (IP adresy, resource IDs, niektóre outputy): zaszyfowany at rest (S3 encryption), zaszyfowany in transit (TLS 1.3), access logged (S3 access logging). Dodatkowa warstwa: Terraform encryption provider (jeśli dostępny) dla szyfrowania sensitive outputs w state.

State locking. DynamoDB (AWS) lub PostgreSQL advisory locks dla zapobiegania jednoczesnym terraform apply z dwóch źródeł (race condition → corrupt state). Lock timeout: 15 minut. Lock force-unlock: wymaga break-glass procedure (113.8).

State backup. State bucket ma włączone versioning — każda zmiana state tworzy nową wersję. Retencja: 90 dni wersji state (pozwala na rollback). Dodatkowo: daily backup state do cold storage. Recovery procedure: w przypadku corrupt state — przywrócenie poprzedniej wersji z S3 versioning, terraform refresh dla reconcilacji.

Segmentacja state. Nie jeden monolityczny state, lecz state per-zone per-region: state-eu-west-management, state-eu-west-ingress, state-eu-west-workload. Izolacja state redukuje blast radius (kompromitacja jednego state nie ujawnia konfiguracji innych stref) i przyspiesza terraform plan/apply (mniejszy state = szybsza operacja).

113.4 Obsługa sekretów w IaC

Status: [N] Normatywny Odbiorca: Infra | Dev | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 113.1, 113.3, 111.6

Sekrety (passwords, API keys, certificates) nigdy nie mogą znajdować się w kodzie Terraform, Ansible playbooks, Git repository ani Terraform state w plaintext.

Vault dynamic credentials. Terraform Vault Provider generuje tymczasowe, krótkoterminowe credentials w runtime: database credentials (PostgreSQL role z TTL 1h), cloud provider credentials (AWS STS assume-role z TTL 15min-1h), Kubernetes ServiceAccount tokens (TTL 1h). Dynamic credentials eliminują: long-lived secrets, secret sprawl, credential sharing. Każdy terraform apply otrzymuje unikalne credentials, logowane w Vault audit log — pełna identyfikowalność „kto użył jakich credentials”.

Ansible Vault (szyfrowanie zmiennych). Wrażliwe zmienne w Ansible (hasła, klucze) szyfrowane Ansible Vault (AES-256). Vault password zarządzany przez HashiCorp Vault (nie plik na dysku). ansible-playbook --vault-password-file=/dev/stdin z Vault CLI pipe. Alternatywnie: Ansible lookup plugin for HashiCorp Vault — zmienne pobierane z Vault w runtime, nie przechowywane w repozytorium.

Zakaz hardcoding. Pre-commit hook skanuje commity pod kątem: patterns (AWS key format, password=, secret=), entropy analysis (wysokoentropowe stringi mogą być kluczami). Narzędzia: gitleaks, trufflehog. Commit z detected secret = blocked push. CI/CD pipeline: secret scanning jako gate (build fails jeśli secret detected).

Terraform state i sekrety. Terraform state może zawierać sensitive values (np. output database password). Mitigation: (a) oznaczanie outputs jako sensitive (Terraform sensitive = true — ukrywa w CLI output, nie w state), (b) external secret management (credentials nie w Terraform, a w Vault — Terraform provision zasób, Vault zarządza credentials), (c) state encryption (113.3). Docelowo: zero secrets w Terraform state — wszystkie credentials przez Vault dynamic.

113.5 Wykrywanie dryftu konfiguracji

Status: [R] Rekomendowany Odbiorca: Infra | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 113.1, 113.3, 113.6, 118.5

Dryft (drift) to różnica między zadeklarowanym stanem infrastruktury (IaC) a stanem rzeczywistym. Dryft jest symptomem: manual change (naruszenie 113.1), external modification (dostawca zmienił coś), lub bug w IaC.

Automated drift detection. CI/CD pipeline uruchamia terraform plan dla każdego state segment: (a) daily (scheduled, 02:00 UTC), (b) on-demand (trigger manualny), (c) post-incident (po każdym incydencie P1/P2). terraform plan porównuje state z rzeczywistością — wynik: „no changes” (OK) lub lista zmian (drift detected).

Alert on drift. Drift detected → alert do kanału #infra-alerts (Slack/Matrix) + ticket w systemie ticketowym. Drift categorization: (a) expected drift (auto-scaling zmienił liczbę nodes — known-good drift), (b) unexpected drift (firewall rule zmieniona manualnie — investigation required), (c) critical drift (security-relevant change: encryption disabled, public IP added — immediate P1 alert).

Auto-remediation dla known-good drift. Dryft spowodowany przez auto-scaling (Kubernetes HPA, cloud auto-scaler) jest oczekiwany i nie wymaga remediation — terraform plan jest skonfigurowany z lifecycle ignore_changes dla tych atrybutów. Dryft spowodowany przez planowe maintenance dostawcy (IP change po migration) — auto-remediation: terraform apply z approval.

Ansible drift detection. Ansible w check mode (–check –diff) uruchamiany daily na production: porównuje desired state (playbook) z actual state (system). Raport diff → review. Ansible drift jest trudniejszy do auto-remediate niż Terraform (Ansible apply może mieć side effects), dlatego wymaga manual review przed remediation.

113.6 Policy-as-code dla infrastruktury

Status: [R] Rekomendowany Odbiorca: Infra | SOC | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 113.1, 113.5, 118.5, 128.4

Policy-as-code zapewnia, że zmiany infrastruktury nie mogą naruszać zdefiniowanych polityk bezpieczeństwa — nawet jeśli developer z uprawnieniami Infra próbuje zmienić coś niezgodnie z wymaganiami.

Narzędzia. HashiCorp Sentinel (Terraform Enterprise/Cloud) lub Open Policy Agent (OPA) z Conftest (open-source alternative). OPA/Conftest rekomendowane dla SYLION (vendor-neutral, open-source, szersza adopcja).

Kluczowe polityki infrastrukturalne:

Policy	Opis	Severity
no-public-ip-zone3	Zasoby w Strefie 3 (workload) nie mogą mieć public IP	Hard mandatory
encryption-everywhere	Wszystkie volumes i buckets muszą mieć encryption enabled	Hard mandatory
no-default-vpc	Zasoby nie mogą być tworzone w default VPC	Hard mandatory
tag-compliance	Wszystkie zasoby muszą mieć tagi: tenant_id, zone, environment	Hard mandatory
ssh-no-password	SSH access musi wymagać key-based auth, nie password	Hard mandatory
approved-instance-types	Tylko zatwierdzone typy instancji (cost control)	Soft (advisory)
region-restriction	Zasoby mogą być tworzone tylko w approved regions	Hard mandatory
firewall-no-allow-all	Firewall rules nie mogą mieć allow 0.0.0.0/0 (z wyjątkiem G1 ingress)	Hard mandatory
hsm-required-state	Deployment STATE musi mieć HSM resource	Hard mandatory

Enforcement. Policy check uruchamiany jako gate w CI/CD pipeline: terraform plan → OPA/Conftest evaluation → pass/fail → terraform apply (only on pass). Hard mandatory policy failure = pipeline fails = brak deploy. Soft advisory = warning w output, deploy proceeds. Policy violation logged do compliance dashboard (118.5).

Policy testing. Każda polityka ma unit tests (OPA/Rego tests): test z known-good configuration (should pass), test z known-bad configuration (should fail). Policy tests uruchamiane w CI na każdy commit do policy repo. Polityki wersjonowane w Git z review process identycznym jak IaC.

113.7 Walidacja i testowanie infrastruktury

Status: [R] Rekomendowany Odbiorca: Infra | Dev Wpływ na baseline: Wysoki Powiązane rozdziały: 113.1, 113.2, 113.6, 128.1

Infrastruktura jako kod wymaga testowania na tych samych zasadach co kod aplikacji: unit tests, integration tests, smoke tests.

Terraform validate + fmt. Uruchamiane jako pre-commit hook i w CI pipeline: terraform validate sprawdza syntaktyczną poprawność konfiguracji, terraform fmt sprawdza formatowanie (code style consistency). Failure = blocked commit/pipeline.

Terratest. Framework do integration testingu modułów Terraform (Go-based): (1) test tworzy infrastrukturę w izolowanym test environment, (2) weryfikuje properties (endpoint accessible, encryption enabled, network isolated), (3) niszczy infrastrukturę. Terratest testy uruchamiane: na każdy PR dotyczący modułów Terraform, nightly dla regression testing. Koszt: test environment w cloud provider (~5-20€ per run, 5-30 min duration).

Infrastructure smoke tests post-deploy. Po każdym deploy (CI/CD post-deploy stage): (a) connectivity check — G1 reachable, G2 reachable from G1, management endpoints reachable, (b) authentication check — Vault unsealed and healthy, Keycloak responsive, (c) provisioning check — test microVM provision and destroy, (d) monitoring check — Prometheus scraping targets, Grafana dashboards loading, (e) security check — TLS certificates valid, firewall rules effective (port scan from external).

Ansible molecule. Ansible role testing framework: molecule test uruchamia role w izolowanym kontenerze, weryfikuje idempotentność (drugi run = no changes), sprawdza desired state (services running, files present, permissions correct). Molecule testy uruchamiane: na każdy PR, nightly.

113.8 Zmiany awaryjne — procedura break-glass IaC

Status: [N] Normatywny Odbiorca: Infra | SOC | CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 113.1, 113.5, 130.7

Procedura break-glass umożliwia emergency changes infrastruktury z pominięciem standardowego flow GitOps, gdy sytuacja wymaga natychmiastowej reakcji (active exploitation, P1 availability incident, security vulnerability requiring immediate patching).

Kiedy break-glass jest dozwolony. Wyłącznie: (a) aktywny atak (exploit in progress, data exfiltration detected), (b) krytyczna podatność z aktywnym exploitation (CVE z CVSS ≥9.0 + known exploit in the wild), (c) P1 availability incident (usługa niedostępna dla >50% operatorów), (d) regulacyjny nakaz natychmiastowy (np. sądowy nakaz zablokowania konta). Nie jest break-glass: planned maintenance, feature deployment, non-critical bugfix.

Procedura: (1) Dual approval — wymagana autoryzacja dwóch osób z listy break-glass approvers (CISO + CTO, lub CISO + Lead Infra, lub CTO + Lead Infra). Approval przez secure channel (FIDO2-authenticated Matrix room, phone call z verification). (2) Time-bounded — break-glass change ma TTL (default 4h, max 24h). Po upływie TTL change musi być: utrwalony w IaC (committed do Git), lub reverted. (3) Execution — break-glass executor łączy się przez management VPN z dedicated break-glass credentials (osobne od daily credentials, stored in Vault, accessed only during break-glass). (4) Logging — każda komenda wykonana

podczas break-glass logowana do SIEM (session recording, command capture). (5) Post-incident — w ciągu 48h: break-glass change musi być zaimplementowany jako IaC commit (terraform + ansible), post-incident review dokumentuje: co zrobiono, dlaczego, jakie były alternatywy, jak zapobiec podobnej sytuacji.

Cleanup obligation. Break-glass change, który nie został utrwalony w IaC w ciągu TTL, jest automatycznie flagowany jako compliance violation w dashboardzie (118.5). Brak cleanup = eskalacja do CISO.

113.9 Dokumentacja modułów infrastrukturalnych

Status: [R] Rekomendowany Odbiorca: Infra | Dev Wpływ na baseline: Średni Powiązane rozdziały: 113.2, 127.1, 131.3

Każdy moduł IaC (Terraform module, Ansible role) musi posiadać dokumentację umożliwiającą jego użycie, modyfikację i review przez osoby inne niż autor.

README per moduł. Obowiązkowa zawartość README.md: (a) Purpose — co moduł robi (1-3 zdania), (b) Architecture — jakie zasoby tworzy (lista lub diagram), (c) Inputs — tabela wszystkich zmiennych z typem, opisem, default, wymagalnością (generowana przez terraform-docs), (d) Outputs — tabela wszystkich outputów z opisem, (e) Dependencies — jakie inne moduły/zasoby wymagane, (f) Examples — minimum 1 przykład użycia (typical deployment), (g) Security considerations — jakie security properties moduł zapewnia/wymaga.

Input/output documentation. Terraform-docs generuje automatycznie dokumentację inputs/outputs z kodu Terraform. terraform-docs uruchamiany jako pre-commit hook — README zawsze synchronizowany z kodem. Ansible: ansible-doc generuje dokumentację ról.

Dependency diagram. Każdy moduł zone-level i platform-level ma diagram zależności (PlantUML lub Mermaid) pokazujący: które moduły component-level wywołuje, jakie dane przekazuje między nimi, jakie external dependencies ma (Vault, DNS, cloud API). Diagram aktualizowany przy zmianach modułu.

CZĘŚĆ XV — ZGODNOŚĆ, PRAWO I REGULACJE

Rozdział 114. Ramy prawne i wymagania branżowe

114.1 Ogólny krajobraz prawny

Status: [N] Normatywny Odbiorca: Compliance | Zarząd | CISO | Prawnik Wpływ na baseline: Krytyczny Powiązane rozdziały: 114.2–114.8, 115.1, 117.1

Europejska Ustawa o Wolności Mediów (EMFA). Rozporządzenie Parlamentu Europejskiego, w pełni obowiązujące od 8 sierpnia 2025, wprost zabrania rządów państw członkowskich UE stosowania oprogramowania szpiegującego (spyware) wobec dziennikarzy i pracowników mediów. EMFA nie jest jednak rozwiązaniem technicznym — jest zakazem prawnym. SYLION dostarcza rozwiązanie techniczne: nawet jeśli Pegasus lub Predator zostanie zainstalowany na terminalu, model thin client oznacza, że na urządzeniu nie ma danych operacyjnych do wyekstrahowania.

SYLION działa na przecięciu wielu jurysdykcji i reżimów regulacyjnych, co wymaga precyzyjnego mapowania obowiązków prawnych na architekturę techniczną i strukturę korporacyjną.

GDPR (Rozporządzenie 2016/679). Fundamentalne rozporządzenie UE o ochronie danych osobowych. SYLION przetwarza dane osobowe operatorów (identyfikatory, metadane sesji, dane rozliczeniowe) i musi spełniać wszystkie wymagania GDPR. Swiss AG jako data controller (dla klientów EU) korzysta z decyzji adekwatności Szwajcarii (Komisja Europejska uznaje Szwajcarię za zapewniającą odpowiedni poziom ochrony danych) — transfer danych EU → CH jest legalny bez dodatkowych zabezpieczeń. Szczegóły: 115.1.

NIS2 (Dyrektywa 2022/2555). Dyrektywa UE o bezpieczeństwie sieci i systemów informacyjnych. SYLION jako dostawca usług cyfrowych (cloud/communication) może podlegać NIS2 w zależności od skali (>50 pracowników lub >10M€ obrotu) i klasyfikacji klientów (essential services). Wymagania NIS2: risk management measures, incident reporting (24h early warning, 72h notification, 1 month report), supply chain security, board-level responsibility. SYLION musi być ready for NIS2 nawet jeśli bezpośrednio nie podlega — klienci (banki, energetyka, administracja) będą wymagać NIS2 compliance od dostawców.

DORA (Rozporządzenie 2022/2554). Digital Operational Resilience Act — regulacja sektora finansowego UE. Klienci SYLION z sektora finansowego (121.1) będą wymagać od SYLION spełnienia wymagań DORA jako ICT third-party service provider: rygorystyczne SLA, incident reporting, resilience testing, exit strategy, audit rights.

Swiss DSG (nDSG). Nowa szwajcarska ustawa o ochronie danych (obowiązuje od 2023). Zbliżona do GDPR, ale z różnicami: brak wymogu DPO (ale rekomendowany), kary do 250K CHF (osobiste, nie korporacyjne), brak obowiązku prowadzenia rejestru czynności przetwarzania (<250 pracowników). Swiss AG podlega nDSG jako primary law.

US CLOUD Act (2018). Ustawa USA umożliwiająca wymuszenie ujawnienia danych przez amerykańskich dostawców, nawet jeśli dane przechowywane za granicą. Mitigation: Swiss AG nie jest amerykańskim podmiotem i nie podlega CLOUD Act. US LLC (dla US market) podlega — ale dane klientów non-US nie są przechowywane/przetwarzane przez US LLC. Struktura korporacyjna celowo izoluje dane europejskie od jurysdykcji amerykańskiej.

Export control laws. EU Dual-Use Regulation (2021/821), US EAR (Export Administration Regulations). Kryptografia silna (AES-256, PQC) podlega kontroli eksportu. ECCN 5E002 dla technologii kryptograficznych. Szczegóły: 114.6.

114.2 Zarządzanie korporacyjne i ład

Status: [R] Rekomendowany Odbiorca: Zarząd | Compliance | CISO Wpływ na baseline: Wysoki Powiązane rozdziały: 114.1, 116.1, 118.1

Klienci enterprise i sektora publicznego oczekują, że dostawca usług bezpieczeństwa sam stosuje najwyższe standardy ładu korporacyjnego. SYLION musi demonstrować dojrzałość organizacyjną.

Board-level security. Zarząd SYLION AG musi: (a) formalnie zatwierdzać strategię bezpieczeństwa (annual review), (b) otrzymywać quarterly security briefing (CISO report: incidents, risk register, compliance status, investment needs), (c) wyznaczać członka zarządu odpowiedzialnego za cyberbezpieczeństwo, (d) zatwierdzać akceptację ryzyk rezydualnych o severity Critical/High.

Audit committee. SYLION AG powinien posiadać komitet audytu (lub rolę w zarządzie) odpowiedzialny za: oversight of financial reporting (rachunkowość), oversight of audit process (ISO 27001, SOC 2), oversight of risk management, liaison z audytorami zewnętrznymi. Komitet audytu raportuje do pełnego zarządu.

Policy frameworks. SYLION powinien wdrożyć formalny framework zarządzania bezpieczeństwem: (a) ISO 27001 ISMS (Information Security Management System) — Year 1 target (116.1), (b) NIST CSF (Cybersecurity Framework) — jako referencja dla gap analysis i komunikacji z klientami US, (c) CIS Controls v8 — jako operational checklist. Polityki obejmują: Information Security Policy (top-level), Acceptable Use Policy, Access Control Policy, Incident Response Policy, Data Protection Policy, Business Continuity Policy, Supplier Security Policy, Cryptographic Policy, Physical Security Policy, Change Management Policy.

Macierz RACI — operacje kluczowe

Operacja	Responsible	Accountable	Consulted	Informed
Provisioning operatora	Ops/DevSecOps	CISO	IT Manager	Operator
Revoke sesji / terminala	SOC Analyst	CISO	Ops Lead	Operator
Modyfikacja polityk G1/G2	DevSecOps	CISO	Auditor	IT Manager
Rebuild środowiska (incydent)	Ops / IaC	Incident Commander	SOC, DevSecOps	CISO, IT Manager
Dual Authorization (destrukcja env)	Admin 1 + Admin 2	CISO	Legal	Auditor
Key Ceremony (HSM/PKI)	PKI Admin	CISO	Auditor, Legal	CTO
Red Team Exercise	External Red Team	CISO	CTO, Legal	Board

Jurisdictional Hopping [A]	Ops / IaC	C-level	Legal, CISO	Auditor
Patch krytyczny (P1 CVSS≥9)	DevSecOps	CISO	Architekt	IT Manager
Certyfikacja (ISO/FIPS/CC)	Compliance	CISO / CTO	Architekt, Legal	Board

114.3 Oczekiwania sektora publicznego

Status: [R] Rekomendowany Odbiorca: Zarząd | Compliance | Sales Wpływ na baseline: Wysoki Powiązane rozdziały: 114.1, 114.4, 119.1, 119.7

Sektor publiczny (Phase 2: defense, government) wymaga spełnienia dodatkowych wymagań wykraczających poza standardowe compliance.

Zamówienia publiczne. W UE: Prawo zamówień publicznych (PZP w Polsce, BōB w Szwajcarii) wymaga: transparentnego procesu przetargowego, spełnienia kryteriów technicznych (certyfikacje, SLA), oświadczeń o niezaleganiu z podatkami, referencji. SYLION musi przygotować standardowy pakiet dokumentów przetargowych (Template w 129.4).

National security vetting. Dla klientów obronnych: personel SYLION z dostępem do infrastruktury klienta może wymagać poświadczenia bezpieczeństwa (security clearance). W Polsce: poświadczenie ABW. W Szwajcarii: Personensicherheitsprüfung. W Niemczech: Sicherheitsüberprüfung. SYLION musi: zidentyfikować role wymagające clearance, wspierać process clearance dla pracowników, zapewnić, że niezwyfikowany personel nie ma dostępu do infrastruktury objętej clearance.

Supply chain security. Klienci rządowi wymagają przejrzystości łańcucha dostaw: skąd pochodzi hardware (router, phone, FIDO2), jakie oprogramowanie open-source jest używane (SBOM — Software Bill of Materials), kto ma dostęp do kodu źródłowego, czy jest supply chain attestation (SLSA).

114.4 Deployementy suwerenne — definicja prawna

Status: [N] Normatywny Odbiorca: Compliance | Zarząd | Architekt | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 110.5, 114.5, 119.1, 119.2

„Suwerenność” (sovereignty) w kontekście SYLION oznacza pełną kontrolę klienta nad danymi i infrastrukturą w ramach jednej jurysdykcji prawnej. Suwerenność to nie marketing — to precyzyjnie zdefiniowany zestaw wymagań.

Cztery wymiary suwerenności:

Data residency — dane przechowywane i przetwarzane wyłącznie na terytorium określonej jurysdykcji. Obejmuje: dane produkcyjne, backupy, logi, klucze kryptograficzne, metadane. Nie dotyczy: danych zanonimizowanych/zagregowanych do celów statystycznych (zgodnie z GDPR recital 26).

Key sovereignty — klucze kryptograficzne przechowywane w HSM na terytorium jurysdykcji, zarządzane przez personel podlegający prawu tej jurysdykcji. Klient może mieć BYO-KMS (own key management), co oznacza, że SYLION nie ma technicznej możliwości odszyfrowania danych klienta bez kooperacji klienta.

Operational sovereignty — infrastruktura zarządzana przez personel z obywatelstwem lub uprawnieniami w danej jurysdykcji (jeśli wymaga tego klient). Remote access z innej jurysdykcji ograniczony lub wyeliminowany. Patching, monitoring, incident response — wszystko w jurysdykcji.

Legal jurisdiction sovereignty — dane podlegają wyłącznie prawu danej jurysdykcji. Struktura korporacyjna SYLION (Swiss AG) zapewnia, że dane europejskie podlegają prawu szwajcarskiemu, nie CLOUD Act. Dla klientów wymagających lokalnej jurysdykcji (np. polska instytucja rządowa wymagająca prawa polskiego) — polska Sp. z o.o. może być stroną umowy, z danymi w Polsce.

114.5 Data residency — wymagania i implementacja

Status: [N] Normatywny Odbiorca: Compliance | Architekt | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 110.4, 110.5, 114.4, 115.7

Data residency jest konfigurowalny per tenant — klient wybiera region przechowywania danych, a SYLION gwarantuje, że dane nie opuszczają tego regionu.

GDPR Art. 44-49 — transfer danych. Transfer danych osobowych poza EOG dozwolony wyłącznie do: (a) krajów z decyzją adekwatności (Szwajcaria, UK, Japonia, Korea Pld., Izrael i inne), (b) z zastosowaniem Standard Contractual Clauses (SCCs) — nowa wersja 2021/914, (c) z Binding Corporate Rules (BCR), (d) z derogacjami Art. 49 (zgoda, konieczność kontraktu). SYLION domyślnie: dane EU clients w Szwajcarii (adequacy decision) lub w wybranym regionie EU (Niemcy, Polska, Francja).

Swiss adequacy decision. Komisja Europejska uznała Szwajcarię za zapewniającą odpowiedni poziom ochrony danych osobowych (decyzja 2000/518/EC, potwierdzona po przyjęciu nDSG). Transfer danych EU → CH jest legalny bez SCCs. Swiss AG jako controller: dane klientów EU mogą być przechowywane w Szwajcarii bez dodatkowych zabezpieczeń prawnych.

Configurable per tenant. Klient przy onboarding wybiera data residency region: (a) Switzerland (default), (b) EU-West (Niemcy/Francja), (c) EU-East (Polska), (d) Nordics (Finlandia/Szwecja), (e) Custom (on request, sovereign region setup). Wybór regionu determinuje: fizyczną lokalizację infrastruktury (110.1), jurysdykcję backupów (111.5), zakres replikacji (110.4). Zmiana regionu post-deployment jest możliwa, ale wymaga migration (110.9) i re-consent klienta.

114.6 Kontrola eksportu

Status: [N] Normatywny Odbiorca: Compliance | Zarząd | Prawnik Wpływ na baseline: Wysoki Powiązane rozdziały: 114.1, 119.3, 119.7

SYLION wykorzystuje zaawansowaną kryptografię (AES-256, PQc, IPsec), która podlega regulacjom kontroli eksportu w wielu jurysdykcjach.

EU Dual-Use Regulation (2021/821). Kryptografia >64-bit symmetric key jest kontrolowana (Category 5, Part 2). AES-256, ML-KEM, ML-DSA podlegają kontroli. Wyjątek: „mass market” (Note 4 to Category 5, Part 2) — jeśli kryptografia jest integralną częścią produktu dostępnego publicznie bez ograniczeń. SYLION może kwalifikować się do wyjątku mass market dla STANDARD/PRO (dostępny komercyjnie). STATE z custom kryptografią i restricted distribution prawdopodobnie nie kwalifikuje się — wymaga license.

US EAR (Export Administration Regulations). Jeśli SYLION zawiera komponenty US-origin (oprogramowanie, algorytmy) — podlega EAR. OpenSSL (US origin), strongSwan (Swiss origin), Linux kernel (mixed) — analiza per-component wymagana. ECCN 5D002 (encryption software), 5E002 (encryption technology). License Exception ENC (§740.17) może mieć zastosowanie dla commercial encryption.

Encryption export restrictions. Kryptografia silna eksportowana do: (a) Embargoed countries (North Korea, Iran, Syria, Cuba, Crimea) — absolutny zakaz, (b) Restricted end-users (military, intelligence, WMD-related) w pewnych krajach — license required, (c) General commercial — zwykle dozwolone z notyfikacją (EU) lub

license exception (US).

SYLION compliance. (1) Maintain per-component export classification (ECCN/dual-use category), (2) Screen customers against denied parties lists (US SDN, EU sanctions), (3) Document export classification in legal filebinder, (4) For STATE-level crypto export: seek legal counsel per-transaction, (5) No delivery to embargoed countries. Odpowiedzialność: General Counsel + Compliance Officer.

114.7 Prawo telekomunikacyjne — punkty styku

Status: [N] Normatywny Odbiorca: Compliance | Prawnik | Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 114.1, 123.4, 123.5, 123.9

SYLION nie jest operatorem telekomunikacyjnym, ale wykorzystuje elementy infrastruktury telekomunikacyjnej i musi znać ograniczenia prawne.

Rotacja IMSI — LEGALNA. IMSI (International Mobile Subscriber Identity) rotation jest oferowana komercyjnie przez operatorów MVNO (np. Cape, Efani). Rotacja IMSI polega na okresowej zmianie tożsamości SIM w sieci komórkowej, utrudniając śledzenie terminala przez IMSI catcher lub tower dump. Jest to legalna operacja — klient po prostu zmienia SIM/profil eSIM, co nie narusza żadnego prawa telekomunikacyjnego. Ograniczenie: EID (eSIM identifier) jest persistent i nie podlega rotacji — zaawansowany adversarz może korelować IMSI changes po EID.

Modyfikacja IMEI — NIELEGALNA. IMEI (International Mobile Equipment Identity) to unikatowy identyfikator urządzenia. Modyfikacja IMEI jest nielegalna w: UE (zgodnie z dyrektywami telekomunikacyjnymi poszczególnych krajów), UK (Mobile Telephones (Re-programming) Act 2002), Indie (Indian Telegraph Act), Australia, oraz 16+ innych krajach. SYLION nie oferuje, nie rekomenduje i nie wspiera modyfikacji IMEI. Moduł autonomiczny [A] dokumentujący tę możliwość zawiera wyraźne ostrzeżenie prawne (123.9). Modyfikacja IMEI może skutkować: karą grzywny, karą pozbawienia wolności, utratą gwarancji urządzenia, problemami z ubezpieczeniem.

Lawful Interception (LI). W UE: dyrektywa o retencji danych (nieważna od 2014, ale poszczególne kraje mają lokalne wymogi), obowiązki LI dla operatorów telekomunikacyjnych (ETSI LI standards). SYLION nie jest operatorem telekomunikacyjnym i nie podlega bezpośrednio obowiązkom LI. Jednak: klienci SYLION mogą podlegać (np. firmy telco), a design SYLION (Zero Trust, no master key) oznacza, że SYLION technicznie nie może przechwycić treści komunikacji operatorów — co jest zamierzone architektonicznie.

CALEA (US). Communications Assistance for Law Enforcement Act — obowiązuje US telecommunications carriers. US LLC SYLION: jeśli klasyfikowany jako „telecommunications carrier” (raczej nie — SYLION to platformowa usługa IT, nie carrier), może podlegać. Mitigation: US LLC nie przechowuje kluczy szyfrujących ani treści komunikacji.

114.8 Ryzyka jurysdykcyjne

Status: [R] Rekomendowany Odbiorca: Zarząd | Compliance | Prawnik Wpływ na baseline: Wysoki Powiązane rozdziały: 114.1, 114.4, 114.7

Ryzyka jurysdykcyjne to ryzyka wynikające z operowania w wielu jurysdykcjach z potencjalnie sprzecznymi wymaganiami prawnymi.

Jurysdykcje wysokiego ryzyka. (a) USA — CLOUD Act, FISA §702, NSL (National Security Letters) mogą wymusić ujawnienie danych przez US entities. Mitigation: Swiss AG jako controller dla non-US clients, US LLC ograniczone do US market, fizyczna separacja danych. (b) Chiny — Cybersecurity Law, Data Security Law, wymóg localisation danych. SYLION nie operuje w Chinach. (c) Rosja — wymóg lokalizacji danych osobowych obywateli RF (Federal Law 242-FZ). SYLION nie obsługuje klientów w Rosji. (d) Kraje Five Eyes (US, UK, CA, AU, NZ) — szerokie uprawnienia surveillance. SYLION minimizuje ekspozycję przez Swiss AG structure.

Struktura korporacyjna jako mitigation. (1) Swiss AG (Zug/Zurich) — commercial entity, controller dla EU/Swiss clients. Szwajcaria nie jest członkiem EU/EEA, ale ma adequacy decision. Szwajcaria nie podlega CLOUD Act. Szwajcarskie prawo wymaga Swiss court order dla ujawnienia danych — znacznie wyższy próg niż US subpoena. (2) US LLC (Delaware) — wyłącznie dla US market. Podlega US law. Dane US clients only. Fizycznie oddzielone od EU/Swiss infrastructure. (3) Polish Sp. z o.o. — operations, development, support. Nie przechowuje danych klientów (processor role). Podlega polskiemu prawu pracy i GDPR. Izolowana od bezpośrednich żądań US agencies.

Scenariusz konfliktu jurysdykcji. Jeśli US agency żąda danych od US LLC dotyczących klienta EU: Swiss AG odmawia (nie podlega US law), US LLC nie posiada danych (dane w Swiss AG infrastructure), Polish Sp. z o.o. nie posiada danych. Architektura celowo uniemożliwia compliance z cross-jurisdictional data demands.

Rozdział 115. Ochrona danych i prywatność

115.1 GDPR — role i obowiązki

Status: [N] Normatywny Odbiorca: Compliance | Prawnik | Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 114.1, 114.5, 115.2–115.9

Data controller (administrator danych). Swiss AG pełni rolę data controller dla danych klientów (tenant organizations): dane konta klienta, dane rozliczeniowe, dane kontaktowe, metadane usługi. Jako controller, Swiss AG: określa cele i sposoby przetwarzania, zapewnia legalność przetwarzania, odpowiada za prawa podmiotów danych, zgłasza naruszenia do organu nadzorczego.

Data processor (podmiot przetwarzający). Cloud providers (Hetzner, AWS, GCP) są procesorami SYLION — przetwarzają dane na polecenie i w granicach instrukcji SYLION. Wymagane: Data Processing Agreement (DPA) z każdym procesorem, obejmujący: cel i czas przetwarzania, rodzaj danych, kategorie podmiotów, obowiązki procesora (bezpieczeństwo, confidentiality, cooperation with audits), prawo SYLION do audytu, obowiązek usunięcia/zwrotu danych po zakończeniu współpracy.

Sub-processors. SYLION musi prowadzić listę sub-procesorów (cloud providers, CDR technology vendor, monitoring SaaS jeśli używany). Klient musi mieć możliwość: (a) zapoznania się z listą sub-procesorów, (b) wyrażenia sprzeciwu wobec nowego sub-procesora, (c) rozwiązania umowy w przypadku braku akceptacji sub-procesora.

DPO (Data Protection Officer). GDPR wymaga DPO gdy: przetwarzanie na dużą skalę danych wrażliwych (art. 37). SYLION: monitorowanie bezpieczeństwa i przetwarzanie metadanych sesji może kwalifikować się. Rekomendacja: wyznaczenie DPO (może być external). DPO: punkt kontaktu dla organów nadzorczych i podmiotów danych, nadzór compliance GDPR, doradztwo w DPIA.

Records of Processing Activities (RoPA). SYLION prowadzi rejestr czynności przetwarzania (Art. 30): dla każdego procesu: cel, kategorie danych, kategorie podmiotów, odbiorcy, transfer poza EOG, retencja, środki bezpieczeństwa. RoPA aktualizowany co najmniej raz w roku lub przy zmianie procesu.

Legal basis. Contract (Art. 6(1)(b)): przetwarzanie danych konta/billing konieczne do realizacji umowy. Legitimate interest (Art. 6(1)(f)): security monitoring, fraud prevention, system performance — po przeprowadzeniu balancing test (interes SYLION vs prawa podmiotu danych).

115.2 Privacy by Design — implementacja architektoniczna

Status: [N] Normatywny Odbiorca: Architekt | Dev | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 115.1, 115.3, 115.9

Privacy by Design (PbD) jest wymagane przez GDPR Art. 25 i jest fundamentalnym principium architektonicznym SYLION. Architektura systemu realizuje PbD na wielu poziomach.

No-data-on-terminal. Terminale operatorskie (Pixel z GrapheneOS) nie przechowują danych operacyjnych — działają jako thin client. Utrata lub skonfiskowanie terminala nie ujawnia danych operatora (poza konfiguracją VPN). To jest PbD na poziomie architektonicznym — decyzja projektowa eliminująca cały wektor ryzyka.

Ephemeral sessions. Sesje operatorskie w Firecracker microVM są domyślnie ephemeral — po zakończeniu sesji microVM jest niszczone razem ze wszystkimi danymi sesji. Brak persistent state oznacza brak danych do ochrony po zakończeniu sesji. Klienci mogą wybrać persistent volumes (dla ciągłości pracy), ale domyślne ustawienie to ephemeral — privacy-first default.

Data minimization w każdym komponencie. G1: loguje source IP (do rate limiting), nie loguje treści ani metadanych sesji. G2: loguje session ID, operator ID, destination microVM — minimum do routingu. microVM: nie loguje treści operatora (treść jest w microVM, pod kontrolą operatora). Monitoring: telemetria agregowana, bez personal data (CPU usage per-host, nie per-operator, chyba że operator performance issue wymaga per-operator metrics — wtedy z ograniczoną retencją).

Configurable retention. Klient definiuje retention dla swoich danych: session metadata (1-90 dni, default 30 dni), audit logs (1-24 miesiące, default 12 miesięcy), billing data (wymagane 7 lat ze względów podatkowych — nie konfigurowalne). Retention enforcement: automated deletion po upływie retention period, z audit trail deletion (log „deleted session metadata older than 30 days for tenant X at timestamp Y”).

Pseudonymization. Tam gdzie to możliwe, identyfikatory operatorów w logach zastępowane pseudonimami (hash operator_id + salt per-log-purpose). Depseudonymizacja możliwa wyłącznie przez IAM (mapping operator_id ↔ pseudonym), z access control i audit logging.

115.3 Minimalizacja danych

Status: [N] Normatywny Odbiorca: Architekt | Dev | Compliance | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 115.1, 115.2, 115.5, 115.9

Pełna inwentaryzacja danych zbieranych przez SYLION, z uzasadnieniem, retencją i klasyfikacją.

Dane zbierane — inwentaryzacja:

Kategoria	Dane	Cel	Retencja	Klasyfikacja
Konto klienta	Nazwa organizacji, kontakt admin, NIP/VAT, adres	Realizacja umowy, fakturowanie	Czas trwania umowy + 7 lat (tax)	Dane osobowe (admin)
Konto operatora	Operator ID (UUID), public key fingerprint, role	Autentykacja, autoryzacja	Czas trwania konta + 30 dni	Dane osobowe (pseudonym)
Metadane sesji	Session ID, timestamp start/end, source IP (hashed), destination microVM	Routing, billing, audit	Konfigurowalne 1-90 dni	Dane osobowe (indirect)
Security telemetry	Failed auth attempts, anomaly scores, firewall drops	Security monitoring	24 miesiące	Dane operacyjne
Billing	Usage records, invoices, payment info	Rozliczenia	7 lat (tax law)	Dane osobowe + finansowe
Infrastructure metrics	CPU, RAM, network, IOPS per-component	Capacity planning, SLA	12 miesięcy (raw), 5 lat (aggregated)	Dane operacyjne
Audit logs	Kto, kiedy, co, wynik — per-action	Compliance, forensics	24 miesiące (2 lata, 5 lat STATE)	Dane operacyjne

Co NIE jest zbierane:

Dane	Powód niez zbierania
Treść komunikacji (wiadomości, rozmowy)	E2EE — SYLION technicznie nie ma dostępu
Pliki operatora (dokumenty, media)	W microVM pod kontrolą operatora
Historia przeglądania operatora	Nie monitorowana, nie logowana
Dane biometryczne (poza FIDO2 local)	FIDO2 biometria lokalna na urządzeniu, nie na serwerze
Lokalizacja GPS operatora	Nie zbierana

Security telemetry ograniczenia. Telemetria bezpieczeństwa musi nie zawierać: treści komunikacji, danych osobowych operatora (nazwisko, email — tylko operator ID), URL odwiedzanych przez operatora, zawartości plików przetwarzanych przez operatora. Telemetria jest ograniczona do metadanych technicznych (IP, port, timestamp, result code).

115.4 Podstawy prawne i role przetwarzania

Status: [N] Normatywny Odbiorca: Compliance | Prawnik Wpływ na baseline: Wysoki Powiązane rozdziały: 115.1, 115.3

Precyzyjne mapowanie ról i podstaw prawnych przetwarzania zapobiega niezgodności z GDPR.

SYLION jako controller. Swiss AG jest administratorem (controller) dla: danych konta klienta (organizacja, kontakt, billing), metadanych usługi (session metadata, usage records), security telemetry (generowana przez SYLION infrastructure). Podstawa prawna: Art. 6(1)(b) — realizacja umowy (konto, billing, session routing), Art. 6(1)(f) — uzasadniony interes (security monitoring, fraud prevention).

SYLION jako processor. Swiss AG jest procesorem (processor) dla: komunikacji operatorów (E2EE — SYLION nie ma dostępu do treści, ale technicznie „przetwarza” w sensie transmisji/storage zaszyfrowanych danych). Klient (organizacja) jest controller dla swoich operatorów. DPA (Data Processing Agreement) między SYLION a klientem definiuje: zakres przetwarzania, instrukcje klienta, prawa audytu.

Sub-processor agreements. SYLION ma DPA z każdym cloud provider (sub-processor). Łańcuch: Client (controller) → SYLION (processor) → Cloud provider (sub-processor). Każde ogniwo łańcucha ma DPA z odpowiednimi zobowiązaniami. SYLION odpowiada przed klientem za działania sub-procesorów.

Special categories (Art. 9). SYLION standardowo nie przetwarza danych specjalnych kategorii (zdrowie, rasa, orientacja). Jednak klienci z sektora zdrowia (121.2) mogą przechowywać dane zdrowotne w microVM — SYLION nie ma dostępu (E2EE + ephemeral microVM), ale DPA musi zawierać klauzulę o danych specjalnych kategorii. Klient odpowiada za compliance Art. 9 w zakresie swoich danych.

115.5 Retencja danych

Status: [N] Normatywny Odbiorca: Compliance | Infra | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 111.1, 115.3, 115.6

Harmonogram retencji per typ danych, z uzasadnieniem prawnym i operacyjnym.

Harmonogram retencji:

Typ danych	Min retencja	Max retencja	Uzasadnienie	Konfigurowalne
Security logs (auth, firewall)	12 miesięcy	24 miesiące	ISO 27001, NIS2	Tak (12-24 mies.)
Audit logs (admin actions)	24 miesiące	60 miesięcy (STATE)	Compliance, forensics	Tak (24-60 mies.)
Session metadata	1 dzień	90 dni	Billing, troubleshooting	Tak (1-90 dni)
Billing records	7 lat	10 lat	Tax law (CH/EU)	Nie (wymóg prawny)
Operator account data	Czas konta	+30 dni po usunięciu	Realizacja umowy	Nie
Client organization data	Czas umowy	+7 lat (tax)	Umowa + tax	Nie
Infrastructure metrics (raw)	7 dni	30 dni	Troubleshooting	Tak
Infrastructure metrics (aggregated)	12 miesięcy	60 miesięcy	Capacity planning	Tak
Backupy (daily)	30 dni	90 dni	DR	Tak
Backupy (monthly)	12 miesięcy	24 miesiące	Compliance	Tak
Forensic evidence	7 lat	Indefinite (case-dependent)	Legal proceedings	Nie (per-case)

Automated deletion. Retention enforcement jest zautomatyzowany: daily cron job skanuje dane per-type per-tenant, identyfikuje dane past-retention, wykonuje deletion, loguje deletion do audit trail. Deletion jest irreversible — po upływie retencji dane są permanentnie usunięte (z wyjątkiem danych w immutable backupach — patrz crypto shredding 111.6).

Crypto shredding. Dla danych w immutable backupach (WORM, nie da się usunąć fizycznie): usunięcie Tenant Key z HSM czyni dane permanentnie nieodczyfrowalnymi, co jest uznawane za equivalent deletion pod GDPR (opinia EDPB).

115.6 Prawa podmiotów danych

Status: [N] Normatywny Odbiorca: Compliance | Prawnik | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 115.1, 115.3, 115.5

GDPR przyznaje podmiotom danych (operatorom) szereg praw, które SYLION musi respektować. Kluczowe jest rozgraniczenie odpowiedzialności: SYLION odpowiada za dane, których jest controller; klient odpowiada za dane swoich operatorów.

Right of access (Art. 15). Operator może żądać kopii swoich danych osobowych. SYLION (controller): może dostarczyć dane konta, session metadata, audit logs dotyczące operatora. Klient (controller dla operatorów): odpowiada za dostarczenie treści komunikacji (jeśli retencjonowane — E2EE komplikuje to). SYLION dostarcza klientowi narzędzia do eksportu danych operatora (admin API: export_operator_data).

Right to erasure (Art. 17). Operator lub klient może żądać usunięcia danych. SYLION: usunięcie konta operatora → usunięcie session metadata, audit logs po retencji compliance (nie natychmiast — retencja compliance jest legal basis dla kontynuacji przetwarzania). Billing data nie podlega erasure (tax law override). Crypto shredding (115.5) dla danych w immutable backups.

Right to data portability (Art. 20). Operator ma prawo do otrzymania swoich danych w ustrukturyzowanym, maszynowo czytelnym formacie. SYLION: export w JSON/CSV dla: konto operatora, session metadata, configuration. Komunikacja: E2EE oznacza, że SYLION nie posiada plaintext — portability komunikacji to odpowiedzialność klienta (Matrix export w przypadku Matrix-based communication).

Right to restriction (Art. 18). Czasowe wstrzymanie przetwarzania. SYLION: technical implementation — account freeze (operator nie może się logować, dane nie są usuwane, nie są przetwarzane poza storage).

Response time. GDPR Art. 12(3): 1 miesiąc na odpowiedź, z możliwością przedłużenia o 2 miesiące (z informacją). SYLION target: 14 dni dla prostych zapytań, 30 dni dla złożonych (export dużych zbiorów danych). Klient ma dashboard do self-service DSR (Data Subject Request) dla swoich operatorów — redukuje obciążenie SYLION support.

115.7 Transfer danych transgraniczny

Status: [N] Normatywny Odbiorca: Compliance | Prawnik | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 114.4, 114.5, 115.1

Transfer danych poza EOG wymaga legal basis pod GDPR Chapter V.

EU → Szwajcaria. Adequacy decision 2000/518/EC (potwierdzona). Transfer legalny bez dodatkowych zabezpieczeń. Swiss AG jako controller w Szwajcarii: dane EU klientów mogą być transferowane do Szwajcarii. To jest domyślny flow dla Klientów EU-based.

CH → US. Brak generalnej adequacy decision dla USA (Privacy Shield unieważniony w Schrems II). US data framework (DPF) od 2023 — jeśli US entity jest certyfikowane. Alternatywnie: SCCs (Standard Contractual Clauses) nowej edycji 2021/914. SYLION US LLC (jeśli przetwarza dane): musi być certyfikowane pod DPF lub stosować SCCs. W praktyce: dane EU klientów NIE są transferowane do USA — fizycznie w Szwajcarii lub regionie EU.

Data residency eliminuje problem. Dla klientów z wybranym data residency region (114.5): dane nie opuszczają regionu → brak transferu transgranicznego → brak potrzeby legal basis pod Chapter V. To jest najprostsza i najsilniejsza mitigation: konfiguracja data residency per-tenant eliminuje cross-border transfer issues.

Transfer impact assessment (TIA). Dla transferów, które są konieczne (np. support z Polski do danych w Szwajcarii): TIA ocenia: czy prawo docelowe zapewnia „essentially equivalent” ochronę (Schrems II standard), jakie supplementary measures stosowane (encryption, pseudonymization, access control). TIA dokumentowane i dostępne dla audytorów.

115.8 Ocena skutków dla ochrony danych (DPIA)

Status: [R] Rekomendowany Odbiorca: Compliance | Prawnik | Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 115.1, 115.2, 115.3

DPIA (Data Protection Impact Assessment) jest wymagana gdy przetwarzanie „może powodować wysokie ryzyko” dla praw i wolności osób fizycznych (GDPR Art. 35).

Kiedy DPIA wymagana. (a) Systematic monitoring — SYLION monitoruje bezpieczeństwo systemowo (security telemetry, anomaly detection). (b) Large scale processing — przy >1000 operatorów przetwarzanie jest na „dużą skalę”. (c) Innovative technology — Confidential Computing, PQC, microVM isolation. Wniosek: SYLION powinien przeprowadzić DPIA dla platformy jako całości.

DPIA SYLION. DPIA platformy obejmuje: (1) Opis przetwarzania — cele, zakres, kontekst (patrz 115.3). (2) Ocena konieczności i proporcjonalności — czy zbierane dane są minimum wymagane (data minimization assessment). (3) Ocena ryzyk — ryzyka dla operatorów (data breach → exposure of identity, unauthorized surveillance, profiling). (4) Środki mitygacji — encryption, ephemeral sessions, access control, retention limits, PbD. (5) Consultation with DPO.

DPIA klienta. Klient deployujący SYLION dla swoich operatorów powinien przeprowadzić własne DPIA obejmujące: sposób użycia SYLION przez organizację, kategorie danych przechowywanych w microVM przez operatorów, dodatkowe ryzyka specyficzne dla branży klienta (np. dane zdrowotne w healthcare). SYLION wspiera DPIA klienta przez: dostarczenie dokumentacji bezpieczeństwa (Księga Systemu), data flow diagrams, privacy information package, consultancy (PRO/STATE).

115.9 Zarządzanie telemetrią prywatności

Status: [N] Normatywny Odbiorca: Architekt | Dev | SOC | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 115.2, 115.3

Telemetria (dane generowane automatycznie przez system do celów monitoringu i bezpieczeństwa) musi być zarządzana z poszanowaniem prywatności operatorów.

Zasada: telemetria ≠ surveillance. Telemetria bezpieczeństwa służy ochronie systemu i operatorów, nie ich inwigilacji. Dlatego: (a) Telemetria nie zawiera treści komunikacji (E2EE uniemożliwia, ale zasada obowiązuje nawet gdyby technicznie było możliwe). (b) Telemetria minimalizuje dane osobowe — operator ID zamiast nazwiska, hashed source IP zamiast plaintext. (c) Telemetria preferuje agregaty — „10 failed logins in last hour” zamiast „operator X failed login at 14:32:07”.

Per-operator telemetria — ograniczenia. Telemetria per-operator (CPU usage, session duration, network bandwidth per-operator) zbierana jest wyłącznie do: capacity planning, SLA compliance, billing verification. Retencja: 7 dni (raw), 30 dni (aggregated). Nie jest używana do: profilowania behawioralnego operatora, oceny produktywności operatora, marketingu. Klient (organizacja) nie ma dostępu do per-operator telemetrii, chyba że: (a) operator wyraził zgodę, (b) telemetria jest konieczna dla bezpieczeństwa (np. anomaly investigation), (c) legal basis (incident response).

Right to audit. Klient PRO/STATE ma prawo do audytu telemetrii zbieranej przez SYLION: (a) request inventory of collected telemetry (odpowiedź: tabela z 115.3), (b) request sample of actual telemetry records (anonimizowane), (c) on-site/remote audit of telemetry pipeline (STATE). SYLION nie może odmówić uzasadnionego żądania audytu telemetrii.

Rozdział 116. Audyty, certyfikacje i raportowanie

116.1 ISO 27001

Status: [R] Rekomendowany Odbiorca: Compliance | Zarząd | CISO Wpływ na baseline: Wysoki Powiązane rozdziały: 114.2, 116.2, 118.4, 116.10

FedRAMP 20x. Program ogłoszony 24 marca 2025 jako fundamentalna reforma procesu FedRAMP. Zastępuje tradycyjny model (koszt \$500K–5M+, timeline 12–36 miesięcy) automatyzacją opartą na Key Security Indicators i danych maszynowo-czytelnych (OSCAL). Phase 1 (Low) zakończona wrzesień 2025 z pierwszymi autoryzacjami w ~2-3 miesiące. Phase 2 (Moderate) kończona kwiecień 2026. Phase 3 planowana Q3-Q4 2026. Szacowane koszty: \$50,000–200,000 (vs \$1–5M tradycyjnie, redukcja 70-90%). FedRAMP nie wymaga obywatelstwa amerykańskiego — firmy zagraniczne mogą uzyskać autoryzację, choć wiele tworzy spółki zależne w USA z przyczyn praktycznych.

Roadmapa certyfikacyjna z szacunkowymi kosztami:

Certyfikacja	Koszt szacunkowy	Timeline	Cel rynkowy
SOC 2 Type II	\$25 000–80 000	6–12 mc	Enterprise credibility
ISO 27001:2022	\$10 000–50 000	6–12 mc	EU enterprise i government
FIPS 140-3 (crypto module)	\$50 000–200 000	12–18 mc	US gov, NATO, regulated
FedRAMP 20x Moderate	\$50 000–200 000	12–24 mc	US federal
Common Criteria / EUCC	\$175 000–750 000	18–36 mc	EU gov i defence
BSI CS (Niemcy)	\$50 000–150 000	12–24 mc	German public sector

Łączny budżet certyfikacyjny 3 lata: ~\$200 000–500 000+. Znaczący overlap kontroli między SOC 2 i ISO 27001 (30-50%) redukuje łączny nakład pracy przy równoległym dążeniu.

ISO 27001 to międzynarodowy standard zarządzania bezpieczeństwem informacji. Certyfikacja ISO 27001 jest Year 1 target dla SYLION i stanowi fundament dla dalszych certyfikacji.

Zakres (scope). Certyfikacja obejmuje: SYLION platform as a service — provisioning, operation, and support of secure communication and remote work environments. Scope includes: management of cloud infrastructure, cryptographic key management, identity and access management, security monitoring, incident response. Physical scope: SYLION office (Polska), managed datacenters (Szwajcaria/UE).

Timeline. Miesiące 1-3: Gap analysis (porównanie aktualnego stanu z wymaganiami ISO 27001:2022). Miesiące 3-6: Remediation (wdrożenie brakujących kontroli, dokumentacji, procesów). Miesiące 6-9: Internal audit (wewnętrzny audyt ISMS). Miesiące 9-10: Management review (przegląd zarządzania). Miesiące 10-12: Stage 1 audit (review dokumentacji) + Stage 2 audit (on-site verification). Miesiąc 12: Certyfikacja (jeśli brak major non-conformities).

Gap analysis approach. Systematyczne porównanie 93 kontroli Annex A (ISO 27001:2022) z aktualnym stanem: (a) kontrole wdrożone i efektywne — zielony; (b) kontrole częściowo wdrożone — żółty; (c) kontrole niewdrożone — czerwony; (d) kontrole nie mające zastosowania — szary (z uzasadnieniem SoA). Priorytet: najpierw kontrole z Annex A bezpośrednio powiązane z security operations (A.8 — Technological controls), następnie organizational controls (A.5), people controls (A.6), physical controls (A.7).

Certification body. Wybór akredytowanego organu certyfikującego (np. BSI Group, TÜV Rheinland, SGS) na podstawie: (a) doświadczenia w certyfikacji cloud/SaaS providers, (b) akredytacji uznawanej w target markets (EU, Szwajcaria, US), (c) dostępności audytorów z doświadczeniem w bezpieczeństwie komunikacji. Surveillance audits: corocznie (Year 2, Year 3). Re-certification: co 3 lata.

Statement of Applicability (SoA). Kluczowy dokument ISO 27001 — deklaracja, które z 93 kontroli Annex A są stosowane, jak są wdrożone, oraz uzasadnienie wyłączeń. SoA SYLION musi uwzględniać specyfikę: (a) brak danych operatorów na serwerach SYLION (no-data-on-terminal + E2EE), (b) multi-tenant architecture, (c) Confidential Computing w tier STATE, (d) modularność (moduły [A] i [E] poza certyfikowalnym rdzeniem).

116.2 SOC 2 Type II

Status: [R] Rekomendowany Odbiorca: Compliance | Zarząd | Sales | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 116.1, 116.9, 118.5

SOC 2 Type II to standard audytu opracowany przez AICPA, szczególnie istotny dla klientów amerykańskich i enterprise. Raport SOC 2 Type II jest planowany równolegle z ISO 27001 w Year 1.

Scope — Trust Service Criteria. SYLION obejmuje trzy z pięciu TSC: (a) Security (CC) — obowiązkowy, obejmuje wszystkie aspekty bezpieczeństwa platformy, (b) Availability (A) — SLA commitments, DR, resilience, (c) Confidentiality (C) — ochrona danych poufnych klientów. Processing Integrity i Privacy: rozważane do włączenia w Year 2.

Audit period. Minimum 6 miesięcy continuous operation (SOC 2 Type I to point-in-time, ale klienci enterprise wymagają Type II). Strategia: miesiące 1-6 (Year 1) — wdrożenie kontroli + SOC 2 Type I jako bridge; miesiące 6-12 — obserwacja operacyjna; miesiąc 12 — SOC 2 Type II raport. Bridge letter pokrywa okres między audytami.

Complementary User Entity Controls (CUECs). SOC 2 raport definiuje kontrole, które musi wdrożyć klient SYLION (complementary controls): (a) zarządzanie poświadczeniami swoich operatorów (hasła, FIDO2), (b) ograniczenie fizycznego dostępu do terminali operatorskich, (c) szkolenia awareness dla operatorów, (d) incident reporting do SYLION. CUECs dokumentowane w raporcie SOC 2 i shared responsibility model (117.4).

Customer-facing sharing. SOC 2 raport udostępniany klientom PRO/STATE na żądanie, pod NDA. Fragment executive summary dostępny dla prospects. Raport nie jest publiczny. Klienci STANDARD otrzymują summary SOC 2 attestation statement.

116.3 FIPS 140-3

Status: [R] Rekomendowany (Year 2) Odbiorca: CISO | Architekt | Compliance Wpływ na baseline: Krytyczny (dla rynku US) Powiązane rozdziały: 119.3, 116.5, 116.7

FIPS 140-3 (Federal Information Processing Standard) to wymaganie dla kryptograficznych modułów używanych przez agencje rządowe USA. Walidacja FIPS 140-3 jest warunkiem koniecznym dla FedRAMP i rynku US Gov.

Moduły wymagające walidacji. (a) HSM — Level 3 (tamper-evident, identity-based authentication). Podejście: wykorzystanie HSM z istniejącą walidacją FIPS 140-3 (Thales Luna, Entrust nShield, AWS CloudHSM). Nie wymaga odrębnej walidacji SYLION. (b) Cryptographic library — strongSwan (IPsec) korzysta z OpenSSL, który posiada walidację FIPS 140-3 (OpenSSL FIPS Provider). SYLION musi zapewnić, że używa validated module w FIPS mode. (c) Custom crypto — jeśli SYLION implementuje custom PQC wrappers, wymagana odrębna walidacja (CMVP). Koszt: €200-500K, czas: 12-24 miesiące.

Validation approach. Preferowane OEM validation: SYLION wykorzystuje już walidowane moduły (HSM vendor + OpenSSL FIPS Provider) i dokumentuje ich użycie w Security Policy. Dla custom components: Cryptographic Module Validation Program (CMVP) przy NIST. Wymaga: (a) Security Policy document, (b) Finite State Model, (c) testowanie przez akredytowane laboratorium (CST Lab), (d) review przez CMVP.

Timeline. Year 2 Q1: identyfikacja wszystkich cryptographic boundaries. Q2: gap analysis (co jest already validated, co wymaga nowej walidacji). Q3-Q4: przygotowanie Security Policy + lab testing. Year 3 Q1-Q2: CMVP review + validation. Estimated cost: €300-600K (lab testing + consulting).

116.4 Common Criteria

Status: [O] Opcjonalny (Year 3) Odbiorca: CISO | Compliance | Sales (sektor publiczny) Wpływ na baseline: Wysoki (dla STATE) Powiązane rozdziały: 119.1, 116.3, 116.5

Common Criteria (ISO 15408) to międzynarodowy standard oceny bezpieczeństwa produktów IT. Ewaluacja CC na poziomie EAL4+ jest celem dla tieru STATE, wymagany przez wiele europejskich agencji rządowych.

Target: EAL4+ (augmented). EAL4 = methodically designed, tested, and reviewed. Augmentation (+): ALC_FLR.3 (systematic flaw remediation) + AVA_VAN.5 (advanced vulnerability analysis). EAL4+ to najwyższy poziom realnie osiągalny bez dostępu ewaluatora do pełnego kodu źródłowego i procesu development (EAL5+ wymaga semi-formal design).

Evaluation approach. (a) Protection Profile (PP): identyfikacja odpowiedniego PP lub opracowanie własnego Security Target (ST). Potencjalne PP: collaborative protection profile for network devices (NDcPP) jako punkt wyjścia, z rozszerzeniami dla secure communication platform. (b) Security Target (ST): dokument

definiujący TOE (Target of Evaluation), security problem definition, security objectives, security functional requirements (SFR), security assurance requirements (SAR).
(c) TOE scope: rdzeń certyfikowalny SYLION (bez modułów [A] i [E]) — G1/G2 gateway, session broker, key management, IAM.

National certification body. Ewaluacja CC prowadzona przez akredytowane laboratorium (ITSEF) pod nadzorem krajowego schematu: BSI (Niemcy) lub ANSSI (Francja) preferowane ze względu na rozpoznawalność certyfikatów w UE. Certyfikat CC uznawany w 31 krajach CCRA (Common Criteria Recognition Arrangement).

Timeline. Year 3 Q1: opracowanie Security Target. Q2: wybór ITSEF. Q3-Year 4 Q2: ewaluacja (12-18 miesięcy typowo dla EAL4+). Year 4 Q2-Q3: certification decision. Koszt: €400-800K.

116.5 FedRAMP

Status: [O] Opcjonalny (Year 4-5) Odbiorca: Sales (US Gov) | Compliance | Zarząd Wpływ na baseline: Krytyczny (dla rynku US Gov) Powiązane rozdziały: 116.3, 116.6, 116.7, 119.1

FedRAMP (Federal Risk and Authorization Management Program) to program autoryzacji CSP dla agencji rządowych USA. FedRAMP authorization jest warunkiem koniecznym dla sprzedaży do US federal agencies.

Prerequisite path. (a) FIPS 140-3 validation (prerequisite — 116.3). (b) SOC 2 Type II (prerequisite — 116.2). (c) US data residency infrastructure (wymagane — dedykowane US region). (d) US entity (SYLION US LLC) jako CSP applicant. (e) 3PAO selection (Third Party Assessment Organization — akredytowane przez FedRAMP).

Authorization levels. FedRAMP Low: basic SaaS, nie odpowiedni dla SYLION. FedRAMP Moderate: większość federal agencies, docelowy dla Phase 3. FedRAMP High: intelligence, defense — odpowiedni dla STATE-level offerings. SYLION target: FedRAMP Moderate initially, High follow-up.

DoD IL4/IL5 path. Po FedRAMP Moderate: DoD Impact Level 4 (Controlled Unclassified Information — CUI) wymaga dodatkowych kontroli DoD SRG. IL5: higher-impact CUI + mission-critical information. DISA PA (Provisional Authorization) na podstawie FedRAMP + DoD SRG gap assessment.

Timeline. Year 4 Q1: FedRAMP readiness assessment (3PAO engagement). Q2-Q3: System Security Plan (SSP) development (800+ pages). Q4: 3PAO initial assessment. Year 5 Q1-Q2: 3PAO full assessment + POA&M remediation. Q3: Authorization package submission. Q4: ATO (Authority to Operate) issuance. Koszt szacunkowy: €500K-1M (3PAO + consulting + infrastructure + ongoing monitoring).

Continuous monitoring. Po autoryzacji: monthly vulnerability scans, annual 3PAO re-assessment, incident reporting to FedRAMP PMO, annual POA&M updates. ConMon costs: €100-200K/year.

116.6 DISA/IL levels

Status: [O] Opcjonalny Odbiorca: Sales (US DoD) | Compliance Wpływ na baseline: Krytyczny (dla DoD) Powiązane rozdziały: 116.5, 119.1

DISA (Defense Information Systems Agency) definiuje Impact Levels (IL) dla klasyfikacji danych i wymagań bezpieczeństwa w chmurze DoD.

IL2 — Public/Non-CUI. Dane publiczne i non-controlled unclassified. Wymaga FedRAMP Moderate baseline. Nie wymaga dedykowanej infrastruktury. Minimalne wymaganie wejściowe dla DoD cloud.

IL4 — Controlled Unclassified Information (CUI). Dane CUI wymagające ochrony (np. procurement sensitive, PII, law enforcement sensitive). Wymaga: FedRAMP Moderate + DoD SRG additional controls, US data residency, US person access only (restricted to US citizens/LPRs for admin access), logical isolation from non-DoD workloads. SYLION approach: dedicated US namespace, US-only admin team, FedRAMP Moderate as foundation.

IL5 — Higher Sensitivity CUI + Mission Critical. Wyższy poziom ochrony dla CUI wymagającego separation od commercial cloud oraz unclassified DoD mission data. Wymaga: IL4 controls + physical/logical separation from commercial tenants, virtual private cloud or dedicated infrastructure, STIG compliance for all components, continuous monitoring with DoD-approved tools.

IL6 — Secret (future). Classified SECRET data. Wymaga: air-gapped infrastructure, SCIF-equivalent physical security, government-owned infrastructure. SYLION: not in current roadmap, ale architecture (sovereign deployment, air-gap capable) is compatible. Would require separate US entity with facility clearance.

SYLION roadmap. Year 4-5: IL4 (alongside FedRAMP Moderate). Year 5-6: IL5 (post-FedRAMP High). IL6: to be assessed based on market opportunity and sponsoring agency.

116.7 CNSA 2.0 alignment

Status: [N] Normatywny Odbiorca: CISO | Architekt | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 116.3, 119.3, 124.6

CNSA 2.0 (Commercial National Security Algorithm Suite) to zestaw algorytmów kryptograficznych zatwierdzonych przez NSA dla ochrony informacji niejawnych (Classified National Security Information). CNSA 2.0 definiuje przejście na kryptografię postkwantową (PQC).

Wymagania CNSA 2.0 — timeline.

Rok	Wymaganie	Status SYLION
2025	Software/firmware signing: ML-DSA-87 preferred	Planowane
2026	Network protocols: PQC support required (hybrid OK)	W realizacji
2027	Web browsers/servers: PQC required for TLS	Gotowe (IPsec PQC)
2028	Legacy crypto deprecation begins	Zgodne (brak RSA <4096)
2030	PQC exclusive — no legacy crypto allowed	Roadmap aligned
2033	Full PQC-only for all applications	Target readiness

Algorytmy CNSA 2.0.

Kategoria	Algorytm	SYLION component
-----------	----------	------------------

Key Exchange	ML-KEM-1024	IPsec IKEv2, Matrix key exchange
Digital Signature	ML-DSA-87	Code signing, certificate PKI
Hash	SHA-384/SHA-512	All hash operations
Symmetric	AES-256	All symmetric encryption
Pre-shared key	AES-256-based	HSM key wrapping

SYLION roadmap alignment. Year 1 (2026): hybrid profiles (ML-KEM + X25519, ML-DSA + Ed25519) deployed as default for PRO/STATE. Year 2: PQC-only option available. Year 3: hybrid profiles as minimum, PQC-only recommended. Year 5 (2030): PQC-only mandatory for all tiers, legacy crypto removed.

Gap analysis. Aktualny stan: (a) IPsec IKEv2 — strongSwan 6.x supports ML-KEM/ML-DSA hybrid. ✓ (b) Matrix — libolm/vodozemac w procesie dodawania PQC support. W toku. (c) Code signing — GPG signatures need PQC migration. Planowane Year 2. (d) Certificate PKI — PQC CA certificates planned. Year 2.

116.8 Customer-specific audits

Status: [R] Rekomendowany Odbiorca: Compliance | Sales | Legal Wpływ na baseline: Średni Powiązane rozdziały: 116.9, 117.4, 120.1

Klienci PRO i STATE mają prawo do przeprowadzenia własnych audytów bezpieczeństwa SYLION. Proces customer audit jest ustandaryzowany, aby zapewnić efektywność i powtarzalność.

Audit package — standard offering. Zamiast indywidualnych audytów, SYLION oferuje standardowy pakiet audytowy: (a) SOC 2 Type II raport (pod NDA), (b) ISO 27001 certyfikat + SoA, (c) Penetration test executive summary (ostatnie 12 miesięcy), (d) Architecture whitepaper (high-level, bez szczegółów implementacyjnych), (e) Security FAQ (odpowiedzi na najczęstsze pytania audytorskie), (f) Vulnerability management report (summary: mean time to remediate, open critical/high CVEs). Pakiet pokrywa 80-90% typowych pytań audytorskich.

Custom audit — PRO tier. PRO klienci mogą: (a) przesłać własny security questionnaire (odpowiedź w ciągu 10 dni roboczych), (b) przeprowadzić remote audit (video call z SYLION security team, review dokumentacji), (c) przesłać third-party auditor questionnaire. Ograniczenie: brak on-site access, brak access to source code, brak access to live production systems.

Custom audit — STATE tier. STATE klienci mogą dodatkowo: (a) on-site audit SYLION operations (z 30-dniowym advance notice), (b) review kodu źródłowego w kontrolowanym środowisku (clean room, no copy), (c) joint penetration testing (customer-appointed pentester + SYLION team), (d) review konfiguracji infrastruktury dedykowanej klienta, (e) interview SYLION security personnel. Audyt STATE podlega osobnemu NDA i security agreement.

Evidence collection automation. System automatycznie gromadzi dowody audytowe: config snapshots, access logs, change records, test results, vulnerability scan results. Eksport na żądanie w formacie: CSV, JSON, PDF. Audit trail: kto, kiedy, co pobrał z evidence store.

116.9 Evidence collection for audits

Status: [R] Rekomendowany Odbiorca: Compliance | SOC | Infra Wpływ na baseline: Wysoki Powiązane rozdziały: 116.1, 116.2, 118.5

Zbieranie dowodów (evidence) to fundament każdego audytu — ISO 27001, SOC 2, FedRAMP czy customer audit. SYLION implementuje zautomatyzowany system gromadzenia i zarządzania evidence.

Typy evidence i źródła.

Kategoria	Przykłady	Źródło	Retencja
Configuration	Terraform state, Ansible facts, policy configs	Zone 5 (mgmt)	2 lata + current
Access logs	IAM events, admin access, break-glass usage	Zone 4 (SIEM)	2 lata
Change records	Git commits, PR reviews, deployment records	GitLab/GitHub	Permanent
Test results	Pentest reports, vulnerability scans, compliance scans	Security tools	2 lata
Incident records	Incident tickets, RCA reports, timeline logs	Ticketing + SIEM	5 lat
Training records	Security awareness completion, role-based training	LMS/HR system	Duration of employment + 1 rok
Policy documents	Current + historical versions of all policies	Document management	Permanent
Crypto evidence	Key rotation records, HSM audit logs, certificate lifecycle	HSM + PKI	5 lat

Automated evidence export. System eksportuje evidence na żądanie lub według harmonogramu (pre-audit): (a) Daily: automated config compliance checks (evidence of continuous monitoring). (b) Weekly: vulnerability scan results, patching status. (c) Monthly: access review evidence, change statistics, incident metrics. (d) On-demand: full evidence package for specific control/criteria.

Evidence integrity. Każdy evidence record zawiera: timestamp, source system, hash (SHA-384), collector identity. Evidence store jest append-only (WORM). Hash chain umożliwia weryfikację, że evidence nie został zmodyfikowany po zebraniu. Retention zgodna z audit requirements (minimum 2 lata, 5 lat dla incydentów).

Evidence mapping. Każdy evidence item jest mapowany do: (a) ISO 27001 Annex A controls, (b) SOC 2 Trust Service Criteria, (c) FedRAMP controls (NIST SP 800-53). Mapowanie umożliwia: „pokaż wszystkie evidence dla kontroli A.8.9 (Configuration management)” — system zwraca kompletny zestaw dowodów.

116.10 Roadmapa certyfikacyjna

Status: [R] Rekomendowany Odbiorca: Zarząd | Compliance | Sales Wpływ na baseline: Wysoki Powiązane rozdziały: 116.1–116.6

Poniższa roadmapa definiuje sekwencję certyfikacji SYLION, z uwzględnieniem zależności, kosztów i wymagań rynkowych.

Year 1 (2026-2027).

Certyfikacja	Timeline	Koszt est.	Wartość biznesowa
--------------	----------	------------	-------------------

ISO 27001	Q1-Q4	€80-150K	Fundament, wymagany przez enterprise
SOC 2 Type II	Q2-Q4 (Type I) → Year 2 (Type II)	€100-180K	Wymagany przez US enterprise

Year 2 (2027-2028).

Certyfikacja	Timeline	Koszt est.	Wartość biznesowa
FIPS 140-3	Q1-Q4	€300-600K	Prerequisite dla FedRAMP
SOC 2 Type II	Q1-Q2 (first full report)	€80-120K	Continuous
PQC hybrid deployment	Q1-Q2	(internal)	CNSA 2.0 compliance

Year 3 (2028-2029).

Certyfikacja	Timeline	Koszt est.	Wartość biznesowa
Common Criteria EAL4+	Q1 start → Year 4 Q2	€400-800K	EU gov procurement
ISO 27001 re-certification	Q4	€40-60K	Maintenance

Year 4-5 (2029-2031).

Certyfikacja	Timeline	Koszt est.	Wartość biznesowa
FedRAMP Moderate	Year 4 Q1 → Year 5 Q3	€500K-1M	US Gov market
DoD IL4	Year 5 Q3-Q4	€200-400K	US DoD market
FedRAMP High	Year 5 start	+€300-500K	Intelligence/DoD

Całkowity koszt certyfikacji: €1.7-3.3M over 5 years. Pokrywany z margin PRO/STATE (112.3) oraz celowego funduszu certyfikacyjnego.

Zależności krytyczne. ISO 27001 → SOC 2 (shared controls). FIPS 140-3 → FedRAMP (prerequisite). SOC 2 → FedRAMP (prerequisite). Common Criteria: niezależna ścieżka (EU market).

Rozdział 117. SLA, umowy i polityki świadczenia usług

117.1 SLA definitions

Status: [N] Normatywny Odbiorca: Sales | Legal | Klient | Zarząd Wpływ na baseline: Krytyczny Powiązane rozdziały: 112.4, 117.2, 117.6

Service Level Agreement (SLA) definiuje gwarantowane parametry usługi SYLION dla każdego tieru. SLA jest integralną częścią umowy z klientem.

Availability SLA.

Parametr	STANDARD	PRO	STATE
Monthly uptime	99.5%	99.9%	99.95%
Max downtime/month	3h 39min	43min	4min 23s
Planned maintenance window	4h/month	2h/month	0 (rolling upgrades)
Measurement	Per-region	Per-region	Per-tenant

Support response times.

Severity	STANDARD	PRO	STATE
P1 (service down)	4h	1h	15min
P2 (major degradation)	8h	2h	30min
P3 (minor issue)	24h	8h	4h
P4 (question/request)	72h	24h	8h

Incident notification.

Event	STANDARD	PRO	STATE
P1 start notification	2h	30min	15min
Initial update	4h	1h	30min
Ongoing updates	Every 4h	Every 1h	Every 30min
Post-incident report	5 business days	3 business days	24h

Recovery objectives.

Parametr	STANDARD	PRO	STATE
RTO (Recovery Time Objective)	8h	4h	1h
RPO (Recovery Point Objective)	24h	4h	1h (sync replication)

SLA credits. Niedotrzymanie uptime SLA: 10% credit za każde 0.1% poniżej target (max 30% monthly fee). Niedotrzymanie P1 response time: 5% credit per incident. Credits jako credit note na kolejną fakturę, nie cash refund. Wyłączenia: force majeure, customer-caused incidents, scheduled maintenance.

117.2 Service descriptions

Status: [N] Normatywny Odbiorca: Sales | Klient | Legal Wpływ na baseline: Wysoki Powiązane rozdziały: 117.1, 112.1, 119.1

Precyzyjny opis zakresu usług w każdym tierze minimalizuje ryzyko sporów i ustala jasne oczekiwania.

STANDARD (400€/user/period, 6 lub 12 miesięcy). Obejmuje: provisioning i zarządzanie 3× microVM VPS per operator, IPsec IKEv2 encrypted tunnel (G1→G2→workload), remote desktop access (RDP over IPsec), secure messaging (Matrix, opcjonalnie +20€), zarządzanie certyfikatami PKI, FIDO2 authentication, basic monitoring i alerting, email support (P3/P4 response), monthly security patches, shared G1/G2 infrastructure z network isolation. Nie obejmuje: dedykowanej infrastruktury, PQC crypto (upgrade available), on-premise deployment, custom integrations, phone support, SLA credits below 99.5%.

PRO (1500€/user/12 miesięcy). Wszystko z STANDARD plus: PQC hybrid mandatory, Enhanced SLA (99.9%), priority support (phone + email, P1 1h response), quarterly security reports, custom policy packs, admin delegation, dedicated account manager, API access for integration, advanced monitoring dashboard, CDR processing, annual penetration test results shared.

STATE (2500€/user, min 50 users, 12 miesięcy). Wszystko z PRO plus: Confidential Computing (AMD SEV-SNP/Intel TDX), PQC mandatory (CNSA 2.0 aligned), dedicated infrastructure (cluster-per-tenant), on-premise deployment option, HSM Level 3 on-site option, 99.9% SLA, 15-minute P1 response, dedicated SOC support, quarterly DR exercises, annual red team engagement, custom feature adaptation, professional deployment service, source code review access (under NDA), sovereign deployment option (full network isolation), extended log retention (5 years).

Optional add-ons (all tiers). Matrix homeserver: +20€/user/month. Additional regions: +80% infrastructure cost per additional region. Custom domain/branding: +50€/month. Enhanced backup (cross-region): included in PRO/STATE, +10€/user for STANDARD.

117.3 Acceptable use

Status: [N] Normatywny Odbiorca: Legal | Klient | Operator Wpływ na baseline: Wysoki Powiązane rozdziały: 117.4, 123.9

Acceptable Use Policy (AUP) definiuje dopuszczalne i zabronione użycie platformy SYLION.

Dozwolone użycie. SYLION przeznaczony jest do: bezpiecznej komunikacji biznesowej i osobistej, bezpiecznej pracy zdalnej (remote desktop), wymiany dokumentów i współpracy, ochrony prywatności komunikacji przed nieautoryzowanym przechwyceniem. Platformę mogą używać: kancelarie prawne (tajemnica adwokacka), dziennikarze (ochrona źródeł), organizacje pozarządowe (ochrona aktywistów), przedsiębiorstwa (ochrona tajemnic handlowych), administracja publiczna (ochrona informacji niejawnych, tier STATE).

Zabronione użycie. Zabrania się: (a) wykorzystywania SYLION do planowania, koordynowania lub wykonywania czynów zabronionych przez prawo, (b) przechowywania lub przesyłania materiałów CSAM (Child Sexual Abuse Material) — zero tolerance, natychmiastowe zamknięcie konta, zgłoszenie do organów ścigania, (c) prowadzenia ataków cybernetycznych z infrastruktury SYLION, (d) reverse engineering platformy SYLION (poza zakresem dozwolonym przez prawo), (e) udostępniania poświadczeń dostępu innym osobom, (f) celowego obchodzenia mechanizmów bezpieczeństwa (poza autoryzowanymi testami penetracyjnymi), (g) nadmiernego obciążania infrastruktury (abuse/DoS).

Konsekwencje naruszenia. Gradacja: (a) ostrzeżenie (minor violations, first offense), (b) tymczasowe zawieszenie konta (repeated violations), (c) natychmiastowe zamknięcie konta (serious violations: CSAM, cyberattack, illegal activity), (d) powiadomienie organów ścigania (jeśli wymagane prawem). SYLION nie monitoruje treści komunikacji (E2EE), ale reaguje na uzasadnione zgłoszenia (np. sądowe nakazy, abuse reports od innych operatorów).

Moduły autonomiczne [A]. Operator korzystający z modułów autonomicznych (np. IMSI rotation, jurisdictional hopping) ponosi pełną odpowiedzialność prawną. SYLION nie weryfikuje legalności użycia modułów [A] w jurysdykcji operatora.

117.4 Shared responsibility model

Status: [N] Normatywny Odbiorca: Klient | Sales | Legal | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 117.2, 120.1, 116.2

Model współdzielonej odpowiedzialności precyzuje, kto odpowiada za poszczególne aspekty bezpieczeństwa i operacji.

Obszar	SYLION	Organizacja klienta	Operator
Infrastruktura platform	✓	—	—
G1/G2 gateway security	✓	—	—
MicroVM provisioning	✓	—	—
IPsec tunnel management	✓	—	—
Patching OS/platform	✓	—	—
HSM/PKI management	✓	—	—
Monitoring & alerting	✓	—	—
Incident response (platform)	✓	Cooperation	—
User provisioning	✓ (technical)	✓ (authorization)	—
FIDO2 credential management	—	✓ (policy)	✓ (device)
Terminal physical security	—	✓ (policy)	✓ (execution)
Content of communications	—	—	✓
Compliance with local laws	✓ (platform)	✓ (use case)	✓ (individual)
Autonomous module usage [A]	—	✓ (approval)	✓ (responsibility)

Data classification	—	✓	—
Operator training	—	✓	✓ (completion)
Incident reporting	✓ (platform)	✓ (to SYLION + own)	✓ (to org)

Kluczowa zasada: SYLION jest odpowiedzialny za bezpieczeństwo platformy (security OF the cloud), klient jest odpowiedzialny za bezpieczeństwo w platformie (security IN the cloud). SYLION nigdy nie ma dostępu do treści komunikacji (E2EE) i nie może ponosić odpowiedzialności za treść. Klient ponosi odpowiedzialność za autoryzację operatorów, szkolenia i compliance z regulacjami właściwymi dla swojej branży.

117.5 Support commitments

Status: [N] Normatywny Odbiorca: Sales | Klient | Support Wpływ na baseline: Średni Powiązane rozdziały: 117.1, 117.2

Zobowiązania supportowe SYLION są zróżnicowane według tieru.

Kanały wsparcia.

Kanał	STANDARD	PRO	STATE
Email	✓	✓	✓
Ticket portal	✓	✓	✓
Phone	—	✓ (business hours)	✓ (24/7)
Dedicated Slack/Matrix channel	—	—	✓
On-site support	—	—	✓ (upon request)
Dedicated account manager	—	✓	✓
Technical account manager	—	—	✓

Języki wsparcia. Tier STANDARD: polski, angielski. Tier PRO: polski, angielski, niemiecki. Tier STATE: polski, angielski, niemiecki, francuski (+ inne na zamówienie).
Godziny wsparcia. STANDARD: pon-pt 9:00-17:00 CET. PRO: pon-pt 8:00-20:00 CET (extended hours). STATE: 24/7/365. P1 incidents: 24/7 dla wszystkich tierów (on-call rotation).
Escalation path. Level 1: Support engineer (initial triage, known issues). Level 2: Platform engineer (complex technical issues). Level 3: Security engineer / Architect (security incidents, architecture issues). Level 4: CISO / CTO (critical incidents, executive escalation). STATE klienci mają direct access do Level 2+.
Proactive support (STATE). Quarterly business review, monthly security briefing, proactive capacity review, early access to security advisories (24h before public disclosure), annual security workshop.

117.6 Incident notification obligations

Status: [N] Normatywny Odbiorca: SOC | Legal | Compliance | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 117.1, 114.1, 118.1

Obowiązki notyfikacyjne SYLION wynikają z: umów SLA, GDPR, NIS2 oraz sektorowych regulacji klientów.

P1 notification (service impact).

Krok	Timeline	Treść
Detection	T+0	Automated alert triggers incident
Triage	T+5min	SOC confirms severity P1
Customer notification start	T+15min (STATE), T+30min (PRO), T+2h (STANDARD)	"Incident in progress, details to follow"
Initial update	T+30min (STATE), T+1h (PRO), T+4h (STANDARD)	Scope, impact, ETA for resolution
Ongoing updates	Every 30min/1h/4h	Progress, workarounds
Resolution notification	At resolution	Confirmed resolution + next steps
Post-incident report (PIR)	24h (STATE), 3 days (PRO), 5 days (STANDARD)	Root cause, timeline, actions taken, prevention measures

GDPR breach notification. Jeśli incydent stanowi naruszenie ochrony danych osobowych (personal data breach): (a) SYLION notyfikuje klienta (data controller) bez zbędnej zwłoki, nie później niż 24h od potwierdzenia naruszenia. (b) Klient (controller) notyfikuje organ nadzorczy (DPA) w ciągu 72h od powzięcia wiadomości (Art. 33 GDPR). (c) Klient ocenia, czy notyfikacja podmiotów danych (data subjects) jest wymagana (Art. 34 GDPR — jeśli high risk to rights and freedoms). (d) SYLION dostarcza klientowi informacje niezbędne do spełnienia obowiązków notyfikacyjnych (zakres naruszenia, kategorie danych, liczba podmiotów, podjęte środki zaradcze).
NIS2 notification. SYLION jako dostawca usług cyfrowych (digital service provider) podlega obowiązkom NIS2: (a) Early warning do właściwego CSIRT: 24h od wykrycia significant incident. (b) Incident notification: 72h z pełną oceną wpływu. (c) Final report: 1 miesiąc z root cause analysis i remediation. Significant incident = wpływa na ciągłość usługi, dotyczy >5% użytkowników, lub powoduje straty >€500K.

117.7 Security commitments

Status: [R] Rekomendowany Odbiorca: Klient | CISO | Sales Wpływ na baseline: Wysoki Powiązane rozdziały: 116.1, 117.1, 118.5

Zobowiązania bezpieczeństwa SYLION wobec klientów.

Penetration testing. Częstotliwość: (a) External pentest: minimum raz rocznie, przeprowadzany przez niezależną firmę (nie tę samą dwa lata z rzędu). (b) Internal pentest / red team: raz na kwartał (PRO/STATE). (c) Scope: full-scope (infrastructure + application + social engineering for red team). (d) Remediation SLA: Critical —

72h, High — 7 dni, Medium — 30 dni, Low — 90 dni. (e) Customer notification: executive summary raportu udostępniany klientom PRO/STATE w ciągu 30 dni od zakończenia testu.

CVE response SLA. (a) Critical CVE (CVSS 9.0+): mitigation within 24h (WAF rule, config change, or temporary workaround), patch within 72h, customer notification immediately upon confirmed impact. (b) High CVE (CVSS 7.0-8.9): mitigation within 48h, patch within 7 days. (c) Medium CVE (CVSS 4.0-6.9): patch within 30 days. (d) Low CVE (CVSS <4.0): next maintenance window. (e) Zero-day in active exploitation: emergency response, immediate mitigation, patch ASAP.

Security advisory publication. SYLION publikuje security advisories: (a) format: standardowy (CVE-ID, severity, affected versions, remediation, credit), (b) kanał: dedicated security advisory page + email to customer security contacts, (c) embargo: coordinated disclosure (90 dni od reported to vendor, lub earlier if in-the-wild exploitation).

Transparency report. Roczny raport transparentności: (a) number of government data requests received (by jurisdiction), (b) number of requests complied with, (c) number of requests challenged, (d) categories of data provided. Swiss AG publication: zgodny z Swiss legal framework (nie wymaga gag orders jak US NSL).

117.8 Change windows

Status: [N] Normatywny Odbiorca: Infra | Klient | SOC Wpływ na baseline: Średni Powiązane rozdziały: 113.8, 117.1

Okna zmian (maintenance windows) definiują dopuszczalne okresy dla planowanych zmian infrastrukturalnych.

Scheduled maintenance windows.

Tier	Window	Frequency	Notification
STANDARD	Wt/Czw 02:00-06:00 CET	Up to 4h/month	72h advance email
PRO	Śr 03:00-05:00 CET	Up to 2h/month	5 business days advance
STATE	Rolling upgrades (no window)	Continuous	10 business days advance for any change

Emergency changes. Zmiany krytyczne (security patches, active exploitation) mogą być wdrożone poza maintenance window: (a) P1 security: natychmiastowo, notyfikacja post-hoc w ciągu 1h. (b) P2 security: w ciągu 24h, notyfikacja przed wdrożeniem (jeśli czas pozwala). (c) Approval: dual approval (on-call engineer + security lead), (d) Roll-back: must have tested rollback plan, (e) Audit: full audit trail of emergency change.

Customer notification requirements. STANDARD: email notification to designated security contact. PRO: email + phone call to account manager. STATE: email + phone + dedicated channel notification + written confirmation of change scope. Zmiany z potencjalnym user impact: wymagana customer approval (PRO/STATE) z minimum 5 (PRO) lub 10 (STATE) business days advance.

Blackout periods. Na żądanie klienta STATE, SYLION respektuje blackout periods (np. koniec kwartału finansowego, wybory) — żadne planowane zmiany w zdefiniowanym okresie. Emergency security patches: wyłączone z blackout (ale z podwyższoną notyfikacją i customer approval).

117.9 Contractual carve-outs for experimental modules

Status: [N] Normatywny Odbiorca: Legal | Klient | Sales Wpływ na baseline: Wysoki Powiązane rozdziały: 123.1, 124.1, 117.2

Moduły eksperymentalne [E] i autonomiczne [A] podlegają odrębnym warunkom kontraktowym, wyłączonym z głównego SLA.

Wyłączenia z SLA. Moduły oznaczone [E] i [A] są explicitie wyłączone z: (a) SLA availability (nie wliczane do uptime calculation), (b) SLA support response times (best-effort support), (c) SLA credits (brak kompensacji za niedostępność modułów [E]/[A]), (d) security commitments (pentest coverage, CVE response SLA), (e) compliance certifications (ISO 27001, SOC 2, FedRAMP scope nie obejmuje [E]/[A]).

Warunki korzystania. Aby aktywować moduł [E] lub [A], klient musi: (a) podpisać odrębny aneks do umowy (Experimental/Autonomous Module Addendum), (b) potwierdzić zrozumienie ryzyk (risk acknowledgment form), (c) dla modułów [A] z konsekwencjami prawnymi (np. IMEI modification): uzyskać niezależną opinię prawną potwierdzającą legalność w swojej jurysdykcji, (d) wyznaczyć osobę odpowiedzialną za moduł (module owner) po stronie klienta.

Odpowiedzialność SYLION. Dla modułów [E]: SYLION odpowiada za: udokumentowanie known limitations, notyfikację o discovered security issues, reasonable effort to fix critical bugs, clear documentation of experimental status. Dla modułów [A]: SYLION odpowiada wyłączenie za: udostępnienie dokumentacji technicznej, zapewnienie, że moduł [A] nie osłabia rdzenia certyfikowalnego. SYLION nie odpowiada za: legalność użycia w jurysdykcji klienta, konsekwencje operacyjne, data loss, security incidents wynikające z modułu [A].

Izolacja kontraktowa. Klauzula firewalling: jakiegokolwiek problemy z modułami [E]/[A] nie stanowią podstawy do rozwiązania umowy głównej, roszczeń odszkodowawczych wobec rdzenia certyfikowalnego, ani kwestionowania certyfikacji SYLION.

Rozdział 118. Zarządzanie ryzykiem i compliance monitoring

118.1 Risk register

Status: [N] Normatywny Odbiorca: CISO | Zarząd | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 118.2, 118.3, 118.4

Rejestr ryzyk (risk register) jest centralnym dokumentem zarządzania ryzykiem SYLION, zgodnym z ISO 27005 i NIST SP 800-30.

Format rejestru.

Pole	Opis
Risk ID	Unikalny identyfikator (RISK-YYYY-NNN)
Category	Strategic / Technical / Operational / Legal / Financial / Reputational
Title	Krótki opis ryzyka
Description	Pełny opis scenariusza ryzyka

Threat source	Adversary class (Ch. 3) lub natural/systemic
Affected assets	Componenty, strefy, dane
Likelihood	1 (Very Low) – 5 (Very High), z uzasadnieniem
Impact	1 (Negligible) – 5 (Catastrophic), z uzasadnieniem
Inherent risk	Likelihood × Impact (1-25), z klasyfikacją: Low (1-6), Medium (7-12), High (13-19), Critical (20-25)
Controls	Lista kontroli mitigujących (z ID kontroli ISO 27001/NIST)
Residual risk	Po uwzględnieniu kontroli
Risk owner	Osoba odpowiedzialna (118.2)
Treatment	Accept / Mitigate / Transfer / Avoid
Status	Open / In treatment / Accepted / Closed
Review date	Data następnego przeglądu

Kategorie ryzyk SYLION. (a) Technical: cryptographic compromise, zero-day exploitation, supply chain attack, HSM failure, key compromise. (b) Operational: operator error, capacity shortage, DR failure, monitoring blindspot. (c) Legal/Compliance: GDPR breach, NIS2 non-compliance, export control violation, IMEI modification liability (jeśli klient użyje modułu [A]). (d) Strategic: market shift, competitor with certification advantage, regulatory change (PQC timeline acceleration). (e) Financial: cost overrun, client churn, certification cost escalation. (f) Reputational: security breach publicity, false positive (falszywe oskarżenie o lukę), association with illegal use by client.

Przegląd. Rejestr przeglądany: (a) Kwartalnie: pełny review wszystkich otwartych ryzyk. (b) Po incydencie: nowe ryzyka identyfikowane w RCA. (c) Przy zmianie regulacyjnej: risk re-assessment. (d) Rocznie: executive risk review (zarząd + CISO).

118.2 Risk owners

Status: [N] Normatywny Odbiorca: Zarząd | CISO | CTO | COO | Legal Wpływ na baseline: Wysoki Powiązane rozdziały: 118.1, 118.3

Każde ryzyko w rejestrze musi mieć wyznaczonego właściciela (risk owner) — osobę odpowiedzialną za monitoring ryzyka i decyzje o treatment.

Mapowanie risk owners.

Kategoria ryzyka	Risk owner	Backup
Security / Cryptographic	CISO	CTO
Technical / Architecture	CTO	Lead Architect
Operational / Availability	COO	VP Infrastructure
Legal / Compliance	General Counsel	External legal advisor
Financial / Cost	CFO	COO
Reputational	CEO	CISO
Strategic / Market	CEO	VP Sales
Third-party / Supply chain	COO	CISO

Odpowiedzialności risk owner. Risk owner musi: (a) monitorować status ryzyka i skuteczność kontroli, (b) decydować o treatment (mitigate, accept, transfer, avoid), (c) eskalować ryzyka powyżej swojego progu akceptacji do Risk Committee, (d) zapewnić zasoby na treatment, (e) raportować status kwartalnie do Risk Committee, (f) uczestniczyć w executive risk review.

Risk Committee. Skład: CEO (chair), CISO, CTO, COO, General Counsel, CFO. Spotkania: kwartalne (regular) + ad hoc (po critical risk identification). Decyzje: akceptacja ryzyk Critical/High, budget allocation for treatment, strategic risk direction.

Delegacja. Risk owner może delegować operacyjny monitoring ryzyka do risk coordinator (np. compliance manager), ale nie może delegować odpowiedzialności za decyzje treatment ani akceptację ryzyka rezydualnego.

118.3 Residual risk acceptance

Status: [N] Normatywny Odbiorca: Zarząd | CISO | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 118.1, 118.2

Ryzyko rezydualne (residual risk) to ryzyko pozostające po wdrożeniu kontroli. Formalna akceptacja ryzyka rezydualnego jest wymagana dla ryzyk powyżej poziomu Low.

Progi akceptacji.

Residual risk level	Akceptacja przez	Proces
Low (1-6)	Risk owner	Self-approval, documented
Medium (7-12)	Risk owner + CISO	Dual sign-off
High (13-19)	Risk Committee	Committee decision, recorded minutes
Critical (20-25)	CEO + Risk Committee	Formal resolution, board notification

Risk Acceptance Statement (RAS). Dla każdego zaakceptowanego ryzyka Medium+: (a) Risk ID i opis, (b) inherent risk score, (c) implemented controls, (d) residual risk score z uzasadnieniem, (e) business justification for acceptance (dlaczego nie mitigujemy dalej: cost, feasibility, residual risk acceptable), (f) conditions for re-

assessment (co spowoduje re-evaluation: threat landscape change, regulatory change, incident), (g) expiry date (max 12 miesięcy — wymaga renewal), (h) signatures (risk owner + approver).

Ryzyka krytyczne nie do zaakceptowania. Pewne ryzyka nie mogą być zaakceptowane — wymagają mitigation lub avoidance: (a) ryzyka naruszające fundamentalne security properties SYLION (Zero Trust compromise, E2EE bypass), (b) ryzyka non-compliance z bezwzględnie obowiązującymi przepisami (GDPR breach, NIS2 violation), (c) ryzyka mogące prowadzić do mass compromise operatorów. Identyfikacja tych ryzyk: na etapie risk register setup, potwierdzona przez Risk Committee.

Annual review. Wszystkie zaakceptowane ryzyka przeglądane raz do roku: (a) czy warunki akceptacji nadal obowiązują, (b) czy pojawiły się nowe kontrole umożliwiające mitigation, (c) czy risk landscape się zmienił, (d) renewal lub zmiana treatment.

118.4 Control mapping

Status: [R] Rekomendowany Odbiorca: Compliance | CISO | Auditor Wpływ na baseline: Wysoki Powiązane rozdziały: 118.1, 116.1, 116.9

Mapowanie kontroli łączy ryzyka z mechanizmami ochronnymi (controls) i dowodami (evidence), tworząc traceability chain: Risk → Control → Evidence.

Struktura mapowania.

Risk ID	Control ID (ISO 27001)	Control ID (NIST 800-53)	Control description	Evidence type	Evidence source	Evidence frequency
RISK-2026-001	A.8.24	SC-28	Encryption at rest	Config scan	Terraform state	Daily
RISK-2026-002	A.8.5	IA-2	MFA authentication	Auth logs	IAM system	Continuous
RISK-2026-003	A.8.9	CM-3	Configuration management	Drift report	Terraform plan	Daily

Dual-framework alignment. Kontrole mapowane jednocześnie do ISO 27001 Annex A i NIST SP 800-53. Mapowanie zapewnia: (a) pokrycie obu frameworków jednym zestawem kontroli (efficiency), (b) przygotowanie do FedRAMP (wymaga NIST 800-53), (c) spełnienie wymagań klientów US (NIST) i EU (ISO).

Automatyzacja mapowania. Narzędzie compliance management (np. Vanta, Drata, custom) automatycznie: (a) sprawdza status kontroli (passed/failed/not applicable), (b) zbiera evidence z connected systems, (c) alertuje na failed controls, (d) generuje compliance reports per framework.

Gaps. Unmapped risks (ryzyko bez przypisanej kontroli) = critical compliance gap. Unmapped controls (kontrola bez ryzyka) = potential waste. Regularny gap analysis: kwartalne sprawdzenie, czy każde ryzyko Medium+ ma assigned control i czy każda kontrola ma evidence.

118.5 Continuous compliance

Status: [R] Rekomendowany Odbiorca: Compliance | SOC | CISO Wpływ na baseline: Wysoki Powiązane rozdziały: 118.4, 116.9, 118.6

Compliance nie jest stanem jednorazowym — to ciągły proces. SYLION implementuje continuous compliance monitoring.

Automated compliance checks. Codzienne automatyczne sprawdzenia: (a) Infrastructure compliance: Terraform drift detection (brak niezatwierdzonej zmiany konfiguracji), encryption at rest enabled (all storage), no public IPs on Zone 3/4/5 resources, network segmentation intact. (b) Access compliance: no stale accounts (>90 days inactive), MFA enabled for all admin accounts, no excessive privileges (least privilege check), no shared credentials. (c) Crypto compliance: certificates not expiring within 30 days, key rotation on schedule, no deprecated algorithms (MD5, SHA-1, RSA<2048). (d) Operational compliance: backups completed successfully, DR test within required cadence, security training completion rates.

Dashboard. Per-framework compliance dashboard: (a) ISO 27001: 93 controls × status (green/yellow/red). (b) SOC 2: Trust Service Criteria × status. (c) CNSA 2.0: algorithm migration progress. (d) GDPR: processing activities × compliance status. (e) Overall compliance score: weighted average (Critical controls weighted 3×, High 2×, Medium/Low 1×).

Exception workflow. Gdy automatyczny check wykryje non-compliance: (a) alert do compliance team, (b) triage (true positive / false positive / known exception), (c) true positive: remediation ticket created, owner assigned, SLA per severity, (d) known exception: verified against exception register (118.7), (e) false positive: rule tuned, documented.

Reporting. Monthly compliance report: (a) executive summary (overall posture, trends), (b) per-framework detail, (c) exceptions and their status, (d) remediation progress, (e) new risks identified. Quarterly: Risk Committee presentation. Annually: board-level compliance report.

118.6 Compliance dashboards

Status: [R] Rekomendowany Odbiorca: CISO | Zarząd | Compliance Wpływ na baseline: Średni Powiązane rozdziały: 118.5, 118.4

Dashboardsy compliance zapewniają real-time visibility nad stanem zgodności SYLION.

Per-framework views.

ISO 27001 dashboard. Widok 93 kontroli Annex A w 4 kategoriach (Organizational, People, Physical, Technological). Dla każdej kontroli: (a) status implementacji (Implemented / Partially / Not implemented / Not applicable), (b) effectiveness (evidence-based: passes all checks / some failures / no evidence), (c) last audit finding (conformity / observation / minor NC / major NC), (d) next review date. Podsumowanie: % kontroli w pełni wdrożonych, % z evidence, open non-conformities count.

SOC 2 dashboard. Widok Trust Service Criteria (CC — Common Criteria for Security, plus Availability, Confidentiality): (a) per-criteria status (Effective / Effective with exceptions / Not effective), (b) complementary controls status (CUECs — are customers implementing their part?), (c) open issues from last audit, (d) bridge letter status (current / expiring / expired).

CNSA 2.0 dashboard. Tabela algorytmów: (a) current deployment (which algorithms in use per component), (b) target (CNSA 2.0 required algorithm), (c) gap (what needs migration), (d) timeline (target migration date vs CNSA 2.0 deadline). Kolor: green (migrated), yellow (in progress), red (not started, deadline approaching).

Executive summary. Single-page view: (a) overall compliance health (green/yellow/red), (b) top 5 open risks, (c) top 5 remediation actions in progress, (d) upcoming audit/certification dates, (e) budget utilization vs plan.

118.7 Exception management

Status: [N] Normatywny Odbiorca: Compliance | CISO | Risk owners Wpływ na baseline: Wysoki Powiązane rozdziały: 118.3, 118.5

Wyjątki (exceptions) od polityk bezpieczeństwa i compliance muszą być formalnie zarządzane.

Proces wyjątku. (a) Requestor składa Exception Request Form (129.6) z: opisem wyjątku, uzasadnieniem biznesowym, analizą ryzyka, proponowanymi kontrolami kompensacyjnymi, proponowanym terminem wygaśnięcia. (b) Review: compliance team ocenia wpływ na compliance posture. (c) Approval: zgodnie z progami z 118.3 (Low: risk owner; Medium: risk owner + CISO; High/Critical: Risk Committee). (d) Documentation: zatwierdzony wyjątek rejestrowany w Exception Register z: exception ID, scope, justification, compensating controls, expiry date, approver.

Ograniczenia. Nie można zatwierdzić wyjątku, który: (a) narusza fundamentalne security properties (Zero Trust, E2EE), (b) łamie bezwzględnie obowiązujące przepisy prawa, (c) tworzy ryzyko Critical bez kontroli kompensacyjnych, (d) dotyczy więcej niż 20% operatorów jednego klienta (systemic exception = wymaga zmiany polityki, nie wyjątku).

Time-bound. Każdy wyjątek ma maksymalny czas obowiązywania: (a) Low risk: 12 miesięcy. (b) Medium risk: 6 miesięcy. (c) High risk: 3 miesiące. (d) Critical risk: wyjątki nie powinny być akceptowane (118.3), ale jeśli Risk Committee zatwierdzi: 30 dni z obowiązkowym review.

Tracking i renewal. Exception Register przeglądany miesięcznie. 30 dni przed wygaśnięciem: notification do owner. Wygasłe wyjątki: automatyczny alert, wymaga renewal lub remediation. Wyjątki bez renewal: eskalacja do CISO.

118.8 Third-party risk

Status: [R] Rekomendowany Odbiorca: CISO | COO | Procurement Wpływ na baseline: Wysoki Powiązane rozdziały: 115.4, 118.1, 118.4

SYLION korzysta z third-party providers (cloud, HSM, CDR, monitoring). Zarządzanie ryzykiem dostawców jest kluczowe.

Third-party inventory. Pełna lista dostawców z: (a) nazwa i jurysdykcja, (b) kategoria (cloud infrastructure, security hardware, software component, professional service), (c) data classification handled (none / metadata / encrypted data / cleartext data), (d) criticality (Critical / High / Medium / Low), (e) contract terms (SLA, data processing agreement, sub-processor agreement), (f) last assessment date.

Assessment methodology. Dla dostawców Critical/High: (a) Initial assessment: security questionnaire (SIG Lite lub custom), SOC 2/ISO 27001 report review, architecture review, data flow analysis. (b) Ongoing monitoring: annual re-assessment, continuous monitoring (news, breach databases, CVE tracking), contract review at renewal. (c) For cloud providers specifically: shared responsibility model review, region/data residency verification, encryption key management review, incident notification SLA.

Key third-party risks.

Dostawca	Risk	Mitigation
Cloud provider (VPS)	Unauthorized access to microVM	Firecracker isolation, encrypted rootfs, no provider access to RAM (SEV-SNP for STATE)
HSM vendor	Supply chain compromise	Multiple vendor qualification, firmware verification, tamper evidence
CDR vendor	Malware bypass	Multi-engine CDR, independent validation, fallback blocking policy
Matrix (Synapse)	Vulnerability in homeserver	Dedicated per-tenant instance, regular patching, network isolation

Sub-processor management. Zgodnie z GDPR: (a) lista sub-processors udostępniana klientom (publicznie lub na żądanie), (b) notyfikacja klientów o zmianach sub-processors (30 dni advance notice), (c) klient ma prawo sprzeciwu wobec nowego sub-processor (contractual right).

118.9 Regulatory watch

Status: [R] Rekomendowany Odbiorca: Legal | Compliance | CISO Wpływ na baseline: Średni Powiązane rozdziały: 114.1, 118.1

Monitoring zmian regulacyjnych (regulatory watch) zapewnia, że SYLION wyprzedza zmiany prawne wpływające na platformę.

Monitorowane regulacje.

Regulacja	Jurysdykcja	Relevance	Monitoring source
GDPR (implementing acts, DPA guidance)	EU	Krytyczna	EDPB, national DPAs
NIS2 (implementing acts)	EU	Krytyczna	ENISA, national CSIRTs
DORA (technical standards)	EU (financjal)	Wysoka	EBA, ESMA, EIOPA
Swiss DSG/nDSG	Szwajcaria	Krytyczna	FDPIC
CLOUD Act developments	USA	Wysoka	DoJ, EFF, legal advisory
EU AI Act	EU	Średnia	European Commission
EU Cyber Resilience Act	EU	Wysoka	ENISA
CNSA 2.0 updates	USA (global impact)	Krytyczna	NSA, NIST
Export control changes	EU/US	Wysoka	EU Commission, BIS
eIDAS 2.0	EU	Średnia	EU Commission

Proces. (a) Monitoring: compliance team + external legal advisory review regulatory sources monthly. (b) Impact assessment: nowa regulacja → analiza wpływu na SYLION (architektura, operacje, kontrakty, certyfikacje). (c) Action plan: jeśli wpływ identified → timeline for compliance, resource allocation, control updates. (d) Communication: wpływ na klientów → advisory published, contract amendments if needed. (e) Documentation: regulatory change log z datą identyfikacji, analizą wpływu, podjętymi działaniami.

Early warning. Dla regulacji w procesie legislacyjnym (np. draft implementing acts): proactive analysis i preparation. Przykład: NIS2 implementing acts — SYLION anticipates requirements i wdraża kontrole przed final publication, aby uniknąć compliance gap.

CZĘŚĆ XVI — SCENARIUSZE SPECJALNE I ROZSZERZENIA ZAAWANSOWANE

Rozdział 119. State Level features i integracje rządowe

119.1 Zakres state-level

Status: [N] Normatywny Odbiorca: Sales | Architekt | CISO | Klient (sektor publiczny) Wpływ na baseline: Krytyczny Powiązane rozdziały: 116.4, 116.5, 119.2–119.8

Tier STATE/SOVEREIGN stanowi najwyższy poziom usługi SYLION, dedykowany klientom z sektora publicznego, obronnego i organizacjom o najwyższych wymaganiach bezpieczeństwa. STATE to nie po prostu „PRO z większym SLA” — to fundamentalnie inny model wdrożenia z własnymi wymaganiami architektonicznymi, kryptograficznymi i operacyjnymi.

Co wyróżnia STATE od PRO. (a) Confidential Computing: AMD SEV-SNP lub Intel TDX obowiązkowe — microVM operatorskie działają w Trusted Execution Environments (TEE), co eliminuje ryzyko dostępu cloud provider do danych w pamięci RAM. W PRO TEE jest opcjonalne, w STATE jest mandatory i weryfikowane attestation. (b) PQC mandatory: kryptografia postkwantowa nie jest opcją — ML-KEM-1024 + ML-DSA-87 obowiązkowe dla wszystkich kanałów. Hybrid z klasycznymi algorytmami dozwolony w okresie przejściowym, ale PQC-only musi być dostępne on demand. (c) Dedicated infrastructure: cluster-per-tenant — żadne zasoby nie są współdzielone z innymi klientami. Dedykowane G1/G2 (nie shared), dedykowane HSM partycje (lub on-premise HSM), dedykowana Zone 5 management plane. (d) Sovereign deployment option: pełna izolacja sieciowa, data residency gwarantowane kontraktowo, deployment w jurysdykcji klienta (on-premise lub sovereign cloud). (e) CC evaluation path: architektura przygotowana do ewaluacji Common Criteria EAL4+ (certyfikowalny rdzeń). (f) Professional deployment service: wdrożenie prowadzone przez zespół SYLION (nie self-service), z assessment środowiska klienta, custom threat model, architecture review. (g) Feature adaptation: możliwość dostosowania funkcjonalności do specyficznych wymagań klienta (custom policy packs, custom integrations, custom UI).

Cennik. 2500€/user/12 miesięcy (minimum 50 users = 125,000€ minimum annual contract). Professional deployment service: wyceniany osobno (typowo €50-200K w zależności od scope). Feature adaptation: wyceniana per-project.

119.2 Wymagania deploymentowe

Status: [N] Normatywny Odbiorca: Infra | Architekt | Sales Wpływ na baseline: Krytyczny Powiązane rozdziały: 109.8, 119.1, 119.8

Wdrożenie STATE wymaga spełnienia rygorystycznych warunków infrastrukturalnych, znacząco przekraczających wymagania PRO.

Minimum 50 operatorów. Wymaganie minimalne wynika z: (a) kosztu dedykowanej infrastruktury (fixed costs rozkładane na użytkowników), (b) potrzeby dedykowanego team SYLION do obsługi STATE klienta, (c) zapewnienia ekonomicznej sensowności dedykowanego deploymentu. Wyjątki: organizacje o szczególnie wrażliwym profilu (np. sądy, trybunały) mogą negocjować niższy próg za wyższą stawkę per-user.

Dedicated infrastructure. STATE deployment wymaga: (a) Dedicated compute: odrębne serwery fizyczne (nie shared hosting), Firecracker microVMs na dedykowanych hostach z AMD SEV-SNP/Intel TDX enabled. (b) Dedicated networking: odrębne VPC/VLAN, dedicated G1 i G2 (no shared gateway with other tenants), dedicated transit links. (c) Dedicated storage: odrębne storage volumes z per-tenant encryption keys z dedykowanego HSM. (d) Dedicated management: odrębna Zone 5 management plane (lub logicznie izolowana partycja z kryptograficzną separacją).

On-premise option. Dla klientów wymagających pełnej kontroli fizycznej: (a) SYLION dostarcza hardware specifications i software images. (b) Klient zapewnia datacenter (Tier III+, fizyczna ochrona, redundancja zasilania/chłodzenia). (c) SYLION deployment team instaluje i konfiguruje on-site. (d) Remote management (opcjonalnie): SYLION zarządza zdalnie przez dedykowany, szyfrowany kanał zarządzania. Klient może wybrać full self-management (wymaga przeszkolonego personelu).

Air-gap capable design. Architektura SYLION jest zaprojektowana do działania w środowisku air-gapped (odcięty od internetu): (a) wszystkie updates dostarczane offline (USB/media z weryfikacją podpisów), (b) telemetria i monitoring lokalne (no phone-home), (c) PKI z lokalnym CA (no external OCSP/CRL dependency), (d) Matrix homeserver w trybie no-federation (zamknięty).

Local key management. STATE klient ma opcję: (a) HSM on-premise (SYLION dostarcza rekomendacje i konfiguruje), (b) Customer-managed keys (BYOK — Bring Your Own Keys — klient generuje master keys, SYLION nie ma dostępu), (c) Split key management (master key split pomiędzy SYLION i klienta — wymagane obie strony do operacji kryptograficznych).

119.3 Wymagania kryptograficzne

Status: [N] Normatywny Odbiorca: Architekt | CISO | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 116.3, 116.7, 119.1

Tier STATE wymaga najwyższego poziomu kryptograficznego, zgodnego z CNSA 2.0 i przygotowanego na ewaluację Common Criteria.

HSM requirements. FIPS 140-3 Level 3 minimum. Level 3 zapewnia: (a) tamper-evidence (fizyczne ślady próby otwarcia), (b) identity-based authentication (nie tylko role-based), (c) physical security mechanisms (zeroization upon tamper detection), (d) environmental failure protection. Dla STATE sovereign: on-premise HSM obligatoryjne (nie cloud HSM). Rekomendowane: Thales Luna 7, Entrust nShield Connect XC, Utimaco SecurityServer.

Algorithmic requirements.

Kategoria	Wymagane	Zabronione
Key exchange	ML-KEM-1024 (primary) + X25519 (hybrid)	RSA <4096, DH <3072, ECDH <P-384
Signature	ML-DSA-87 (primary) + Ed25519 (hybrid)	RSA <4096, DSA, ECDSA <P-384
Symmetric	AES-256-GCM, AES-256-CTR	AES-128, DES, 3DES, RC4, ChaCha20 (insufficient for STATE)
Hash	SHA-384, SHA-512, SHA3-384, SHA3-512	MD5, SHA-1, SHA-256 (insufficient for STATE)

MAC	HMAC-SHA-384, HMAC-SHA-512	HMAC-SHA-256, HMAC-MD5
TLS/IPsec	TLS 1.3 only, IKEv2 with PQC profiles	TLS 1.2, IKEv1

Crypto agility. STATE architektura musi umożliwiać: (a) wymianę algorytmu kryptograficznego bez rekonfiguracji całego systemu (config-driven algorithm selection), (b) jednoczesne wspieranie wielu profili kryptograficznych (dla okresu przejściowego), (c) emergency crypto migration (w przypadku złamania algorytmu) w ciągu 72h (config change, nie code change).

No deprecated crypto. W środowisku STATE absolutnie zabronione: MD5 (w jakimkolwiek kontekście), SHA-1 (w jakimkolwiek kontekście), RSA <4096 bit (nawet dla legacy compatibility), DES/3DES (nawet w nested protocols), RC4, NULL cipher suites. Automated scanning wykrywa i blokuje deprecated crypto.

119.4 Wymagania operacyjne

Status: [N] Normatywny Odbiorca: SOC | Infra | CISO | Klient Wpływ na baseline: Krytyczny Powiązane rozdziały: 117.1, 119.1, 119.5

Operacje STATE wymagają dedykowanego poziomu wsparcia i monitoring.

Dedicated SOC support. STATE klienci obsługiwani przez dedykowany zespół SOC (lub wydzieloną partycję SOC z separacją danych od innych klientów): (a) 24/7 monitoring dedykowanej infrastruktury klienta, (b) dedykowane runbooki per klient (uwzględniające specyfikę wdrożenia), (c) proactive threat hunting (nie tylko reactive monitoring), (d) monthly threat intelligence briefing dla security team klienta.

SLA 99.95%. Availability 99.95% oznacza max 4min 23s downtime/miesiąc. Wymaga: (a) active-active multi-region (failover <30s), (b) rolling upgrades (zero-downtime deployments), (c) redundancja wszystkich komponentów (no single point of failure), (d) automated failover (nie zależny od human intervention). Measurement: per-tenant (nie per-region jak w STANDARD/PRO).

RTO <1h. Recovery Time Objective <1h po katastrofie (complete region failure). Wymaga: (a) warm standby w secondary region (pre-provisioned infrastructure), (b) synchronous replication kluczowych danych (IAM state, active sessions, PKI), (c) automated DR activation (runbook-driven, ale human-triggered — auto-failover dla individual components, manual trigger dla full region evacuation), (d) quarterly DR exercises (119.4 wymaga, 117.1 definiuje SLA).

Quarterly DR exercises. Co kwartał: (a) tabletop exercise (discussion-based, all stakeholders), (b) technical exercise (actual failover to secondary region, verification of data consistency, performance validation), (c) report: exercise findings, gaps identified, remediation actions, next exercise plan. Klient STATE ma prawo uczestniczenia w ćwiczeniach DR.

On-site training. SYLION zapewnia: (a) initial deployment training (admin team klienta), (b) annual refresh training, (c) incident response training (joint exercises z SOC klienta), (d) security awareness dla operatorów klienta.

Annual red team. Coroczna kampania red team przeciwko STATE deployment: (a) scope: full-scope (network, application, social engineering, physical jeśli on-premise), (b) execution: niezależna firma (nie ta sama co pentest provider), (c) report: detailed findings + remediation plan, (d) re-test: weryfikacja remediation w ciągu 90 dni.

119.5 Wymagania forensics i evidence

Status: [N] Normatywny Odbiorca: SOC | Legal | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 111.8, 116.9, 119.4

Tier STATE wymaga rozszerzonej zdolności forensics i gromadzenia dowodów.

Extended log retention. Logi bezpieczeństwa przechowywane przez 5 lat (vs 2 lata dla STANDARD/PRO). Dotyczy: (a) authentication logs, (b) access control events, (c) admin operations, (d) configuration changes, (e) security alerts, (f) network flow metadata (no content). Storage: WORM (Write Once Read Many), append-only, hash chain verified.

Forensic evidence packaging. Na żądanie klienta lub organu ścigania (z odpowiednią podstawą prawną): (a) evidence package: logi, konfiguracja, metadata sesji, sformatowane w standardzie forensic (hash chain, timestamps, collector identity), (b) chain of custody documentation: kto zbierał, kiedy, z jakiego systemu, jak transportowano, kto miał dostęp, (c) expert witness capability: SYLION security team dostępny jako świadek-ekspert (biegły) w postępowaniach prawnych dotyczących platformy.

Chain of custody documentation. Formalne dokumentowanie łańcucha dowodowego: (a) evidence creation: timestamp, system, automatic hash (SHA-384), (b) evidence collection: collector identity, method, tools used, (c) evidence transfer: from system to evidence store, encrypted transit, verification hash, (d) evidence storage: WORM storage, access logging (kto, kiedy odczytał evidence), (e) evidence release: to whom, on what basis (court order, legal request), verification that correct evidence released.

Cooperation protocol with national authorities. Protokół współpracy z organami ścigania i służbami specjalnymi: (a) Swiss legal framework jako primary: SYLION Swiss AG odpowiada na żądania prawne zgodnie z prawem szwajcarskim (IMAC — International Mutual Legal Assistance in Criminal Matters). (b) Żądanie z innej jurysdykcji: wymaga MLAT (Mutual Legal Assistance Treaty) przez Szwajcarię. (c) Emergency disclosure: w sytuacjach zagrożenia życia — SYLION może ujawnić ograniczone metadata (nie treść, która jest E2EE) bez court order, zgodnie z Swiss law. (d) Transparencja: każde żądanie dokumentowane, uwzględniane w annual transparency report (117.7).

119.6 Sovereign communications

Status: [O] Opcjonalny Odbiorca: Architekt | CISO | Klient (sovereign) Wpływ na baseline: Wysoki Powiązane rozdziały: 124.3, 119.1, 110.5

Sovereign communications to opcjonalne rozszerzenie STATE, zapewniające najwyższy poziom izolacji i anonimowości.

Dark-Matrix deployment [O]. Matrix homeserver jako Tor v3 hidden service (.onion): (a) no public IP address — homeserver dostępny wyłącznie przez sieć Tor, (b) triple encryption: E2EE (Matrix Megolm/MLS) + Tor onion routing encryption + IPsec tunnel (dla transportu wewnątrz SYLION), (c) no ISP subpoena possible — ISP nie widzi, że serwer hostuje komunikator (traffic wygląda jak random Tor traffic), (d) federation between .onion homeservers — komunikacja pomiędzy sovereign deployments bez wychodzenia z sieci Tor.

Ograniczenia Dark-Matrix. (a) Latency: Tor dodaje 200-500ms latencji — komunikacja real-time (voice/video) znacząco utrudniona. (b) Reliability: Tor circuits mogą się zrywać — wymaga reconnect logic. (c) Complexity: utrzymanie Tor hidden service wymaga dodatkowej infrastruktury i monitoringu. (d) Regulatory: w niektórych jurysdykcjach samo korzystanie z Tor może wzbudzać podejrzenia (ale nie jest nielegalne w EU/US/CH).

Air-gap capable Matrix homeserver. Matrix Synapse w trybie pełnej izolacji: (a) no internet connectivity (air-gapped network), (b) no federation (federation disabled), (c) local CA for TLS certificates, (d) local key server, (e) updates via offline media (USB with signature verification). Use case: classified-adjacent communications, military deployments, embassies in hostile states.

No external federation. Sovereign Matrix deployment nie federuje z żadnymi zewnętrznymi serwerami Matrix. Komunikacja ograniczona do operatorów tego samego sovereign deployment. Rationale: federation wprowadza trust dependency na zewnętrzne serwery, co jest nie do zaakceptowania w kontekście sovereign.

Closed crypto boundary. Wszystkie operacje kryptograficzne w obrębie sovereign deployment używają keys generated i stored wyłącznie w infrastrukturze klienta (on-premise HSM). Żadne klucze nie opuszczają crypto boundary. Key ceremony: initial key generation w obecności klienta z dokumentacją (dual control, split knowledge).

119.7 Ograniczenia prawne i kontraktowe

Status: [N] Normatywny Odbiorca: Legal | Sales | Compliance Wpływ na baseline: Wysoki Powiązane rozdziały: 114.6, 119.1, 117.9

Wdrożenie STATE podlega dodatkowym ograniczeniom prawnym, wynikającym ze specyfiki sektora publicznego i obronnego.

Government procurement. Zamówienia publiczne podlegają: (a) EU: dyrektywy zamówień publicznych (2014/24/EU) — otwarte procedury, wymogi transparentności, (b) Polska: PZP (Prawo Zamówień Publicznych) dla polskiej administracji, (c) Defence procurement: dyrektywa 2009/81/EC (możliwość wyłączeń ze względu na bezpieczeństwo narodowe), (d) US: FAR/DFARS (Federal Acquisition Regulation / Defense Federal Acquisition Regulation Supplement) — dla US Gov via SYLION US LLC.

Security clearance. Dla wdrożeń STATE z dostępem do informacji niejawnych: (a) personel SYLION z dostępem do infrastruktury klienta może wymagać poświadczenia bezpieczeństwa (security clearance), (b) poziom clearance zależy od klasyfikacji danych (POUFNE, TAJNE w polskim systemie; CONFIDENTIAL, SECRET w NATO), (c) SYLION jako organizacja może wymagać Industrial Security Clearance (w Polsce: świadectwo bezpieczeństwa przemysłowego od ABW). (d) Konsekwencja: ograniczona pula personelu SYLION z clearance — wymaga planning.

National security agreements. Dla klientów government/defence: (a) Non-Disclosure Agreement na poziomie państwowym (government NDA), (b) Security agreement (zobowiązanie do ochrony informacji niejawnych), (c) Supply chain disclosure (SYLION musi ujawnić kluczowych dostawców i ich jurysdykcje), (d) Source code escrow (na wypadek bankructwa SYLION — klient ma dostęp do kodu).

Export control compliance. SYLION z PQC kryptografią podlega kontroli eksportu: (a) EU dual-use regulation (Regulation 2021/821): ECCN 5A002 (information security systems), 5D002 (software), 5E002 (technology), (b) Licencja eksportowa może być wymagana dla STATE deployments poza EU/EEA/CH, (c) US EAR: jeśli SYLION zawiera US-origin components (np. AMD SEV-SNP firmware), (d) SYLION legal team weryfikuje compliance przed każdym STATE deployment w nowej jurysdykcji.

119.8 Minimalny baseline state-level

Status: [N] Normatywny Odbiorca: Architekt | Infra | CISO | PM Wpływ na baseline: Krytyczny Powiązane rozdziały: 119.1–119.7

Przed uruchomieniem STATE deployment, poniższa checklist musi być w 100% spełniona (no exceptions, no partial deployment).

Infrastructure checklist.

- ☐ Dedicated compute hosts provisioned (AMD SEV-SNP or Intel TDX verified)
- ☐ Dedicated G1/G2 gateways deployed and tested
- ☐ Dedicated VPC/VLAN with no cross-tenant connectivity
- ☐ HSM provisioned (FIPS 140-3 Level 3) — on-premise or dedicated cloud partition
- ☐ Storage encrypted (AES-256-GCM, per-tenant keys from HSM)
- ☐ Backup infrastructure ready (cross-region, immutable, tested)
- ☐ DR site provisioned and tested (failover <1h verified)
- ☐ Monitoring infrastructure dedicated (no data leakage to shared monitoring)
- ☐ Network segmentation verified (penetration test of isolation)

Cryptographic checklist.

- ☐ ML-KEM-1024 + ML-DSA-87 deployed for all channels
- ☐ AES-256-GCM for all symmetric encryption
- ☐ SHA-384+ for all hash operations
- ☐ No deprecated algorithms in any component (scan verified)
- ☐ Key ceremony completed (documented, dual control)
- ☐ Certificate PKI initialized with PQC algorithms
- ☐ Crypto agility tested (algorithm switch procedure verified)

Operational checklist.

- ☐ Dedicated SOC monitoring active (24/7)

- ☐ Runbooks customized for this deployment
- ☐ DR exercise completed (at least one tabletop + one technical)
- ☐ Incident response plan reviewed with customer
- ☐ Escalation contacts established (SYLION + customer)
- ☐ On-site training delivered to customer admin team
- ☐ Security awareness training delivered to operators

Compliance checklist.

- ☐ Data Processing Agreement signed
- ☐ SLA agreement signed (99.95% availability)
- ☐ Acceptable Use Policy signed by customer
- ☐ Shared responsibility model acknowledged
- ☐ Risk register initialized (deployment-specific risks)
- ☐ Export control clearance verified (if applicable)
- ☐ Security clearance obtained (if applicable)

Sign-off. Deployment go-live wymaga written sign-off od: SYLION CTO, SYLION CISO, Customer Security Officer, Customer Project Sponsor. Brak sign-off = no go-live.

Rozdział 120. Rozszerzenia korporacyjne i multi-tenant hardening

120.1 Enterprise governance overlays

Status: [R] Rekomendowany Odbiorca: Architekt | Compliance | Klient enterprise Wpływ na baseline: Wysoki Powiązane rozdziały: 117.4, 119.1, 120.2

Enterprise governance overlays to dodatkowe warstwy polityk i kontroli nałożone na standardowy baseline SYLION, dostosowane do specyficznych wymagań korporacyjnych klienta.

Custom policy packs. Klient PRO/STATE może zdefiniować własne polityki, wdrażane do swojego środowiska: (a) password policy (minimalna złożoność, maksymalny wiek, historia — ponad SYLION baseline), (b) session policy (max session duration, idle timeout, concurrent session limit), (c) access policy (allowed IP ranges, geo-blocking, time-of-day restrictions), (d) data policy (mandatory encryption labels, DLP rules, retention overrides). Polityki definiowane w formacie OPA/Rego i wdrażane przez pipeline IaC (113.6).

Custom RBAC. Klient może definiować własne role (ponad standard SYLION roles): (a) custom roles z granular permissions (np. „Auditor Read-Only”, „Regional Admin”, „Compliance Viewer”), (b) role hierarchy (regional admin → local admin → operator), (c) role constraints (max operators per role, mandatory dual-role for sensitive operations).

Delegation models. Hierarchiczna delegacja uprawnień: (a) SYLION Admin → Tenant Admin (customer) → Regional Admin → Team Lead → Operator. (b) Każdy poziom deleguje podzbiór swoich uprawnień w dół. (c) Delegation audit trail: kto delegował co komu i kiedy. (d) Revocation cascade: cofnięcie uprawnień na wyższym poziomie automatycznie cofa na niższych.

120.2 Segregated tenants

Status: [R] Rekomendowany Odbiorca: Architekt | Infra | CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 109.8, 119.2, 120.7

Segregacja tenantów zapewnia, że dane i operacje jednego klienta są w pełni izolowane od innych.

Cluster-per-tenant (STATE). Najwyższy poziom izolacji: (a) dedicated Kubernetes cluster (lub dedicated bare-metal hosts) per tenant, (b) dedicated network namespace (no IP overlap possible), (c) dedicated storage volumes (physically separated or encrypted with unique keys), (d) dedicated management plane instance (Zone 5), (e) dedicated monitoring stack (separate Prometheus/Grafana). Cost: highest (112.4), ale eliminuje lateral movement risk.

Namespace-per-tenant (PRO). Izolacja na poziomie Kubernetes namespace: (a) dedicated namespace z resource quotas, (b) network policies (deny-all default, explicit allow per service), (c) dedicated service accounts (no cross-namespace access), (d) dedicated encryption keys (per-tenant keys from shared HSM), (e) shared control plane but isolated data plane. Risk: shared kernel — mitigated by Firecracker microVM isolation.

Shared-with-network-isolation (STANDARD). Współdzielone zasoby z izolacją sieciową: (a) Firecracker microVM per operator (strong isolation), (b) network policies per microVM (no direct microVM-to-microVM communication), (c) shared G1/G2 but per-operator IPsec tunnels, (d) shared monitoring with per-tenant data separation (tenant label filtering). Risk: shared infrastructure — acceptable for STANDARD threat model.

Tenant isolation verification. Quarterly automated verification: (a) network scan: no cross-tenant connectivity possible, (b) storage scan: no cross-tenant data access possible, (c) management scan: no cross-tenant admin operations possible, (d) results documented and available for audit.

120.3 Shared services isolation

Status: [R] Rekomendowany Odbiorca: Architekt | Infra Wpływ na baseline: Wysoki Powiązane rozdziały: 120.2, 109.8, 111.6

Nawet w modelu shared infrastructure, usługi współdzielone (SIEM, monitoring, PKI) muszą zapewniać per-tenant isolation.

Per-tenant encryption keys. Każdy tenant posiada unikalne klucze szyfrowania dla: (a) storage at rest (per-tenant DEK derived from tenant KEK w HSM), (b) log encryption (per-tenant encryption — SIEM nie może odczytać logów innego tenanta bez klucza), (c) backup encryption (per-tenant backup keys). Nawet jeśli storage jest fizycznie współdzielony, kryptograficzna separacja zapewnia, że compromise jednego tenanta nie daje dostępu do danych innego.

Access control per shared service. (a) SIEM: tenant-label mandatory na każdym log entry, query engine wymusza tenant filter (no cross-tenant queries), admin access wymaga explicit tenant context. (b) Monitoring: per-tenant dashboards, per-tenant alerting rules, no cross-tenant metric visibility. (c) PKI: per-tenant CA (sub-CA of SYLION root), per-tenant certificate namespaces, no cross-tenant certificate issuance.

Data leakage prevention. (a) Shared services logs: scrubbed of cross-tenant identifiers before any shared analysis. (b) Aggregated metrics: tenant-anonymous (np. „average CPU across all microVMs” — bez identyfikacji, który tenant). (c) Error messages: no tenant data in shared error logs (parameterized logging).

120.4 Admin delegation

Status: [R] Rekomendowany Odbiorca: Klient | Architekt | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 120.1, 130.4, 117.4

Model delegacji adminów zapewnia, że klient zarządza swoimi operatorami bez dostępu SYLION do danych klienta.

Customer admin capabilities. Customer Admin (Tenant Admin) może: (a) provisioning/deprovisioning operatorów (w ramach zakontraktowanej liczby), (b) zarządzanie rolami operatorów (w ramach dostępnych ról), (c) konfiguracja polityk klienta (session timeout, password policy, access restrictions), (d) przeglądanie logów operatorskich (w ramach swojego tenanta), (e) generowanie raportów compliance dla swojej organizacji, (f) zarządzanie FIDO2 credentials operatorów (reset, revoke).

SYLION admin isolation. SYLION admin NIE MA dostępu do: (a) treści komunikacji operatorów (E2EE), (b) per-operator session data (klient może zablokować access), (c) customer-specific policy configurations (read-only for support, no write without customer approval). SYLION admin MA dostęp do: (a) infrastructure management (platform level), (b) monitoring/alerting (aggregated, per-tenant label), (c) incident response (z notyfikacją klienta).

Break-glass for SYLION. W sytuacji awaryjnej (np. customer admin locked out, platform-level incident): (a) SYLION może aktywować break-glass access do tenant management (nie do danych operatorów), (b) wymaga: dual approval (2 SYLION senior staff), time-bounded (max 4h), full audit trail, customer notification within 1h, (c) post-incident: audit log udostępniony klientowi, break-glass access reverted.

120.5 Tenant-level custom policy packs

Status: [O] Opcjonalny Odbiorca: Klient | Compliance | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 120.1, 113.6, 118.5

Custom policy packs umożliwiają klientom wdrażanie własnych polityk bezpieczeństwa ponad baseline SYLION.

Zakres policy packs. Klient może definiować polityki w obszarach: (a) Authentication: wymagania MFA ponad SYLION baseline (np. FIDO2 mandatory — already SYLION default, ale klient może dodać certificate-based auth), (b) Session management: custom timeouts, geo-restrictions, device restrictions, (c) Network: allowed source IPs, VPN requirements, geo-blocking, (d) Data: classification labels, mandatory encryption, DLP rules, retention overrides, (e) Compliance: custom audit logging (additional events beyond SYLION default), custom compliance checks.

Wdrożenie. Policy packs definiowane w OPA/Rego (125.4), testowane w staging environment, wdrażane przez CI/CD pipeline. SYLION review: każdy custom policy pack przeglądany przez SYLION security team przed wdrożeniem (aby zapewnić, że nie osłabia baseline security).

Ograniczenia. Customer policy packs NIE mogą: (a) osłabiać SYLION baseline security (np. wyłączać MFA, zmniejszać encryption strength), (b) wpływać na innych tenantów, (c) modyfikować certyfikowalny rdzeń, (d) zmieniać zachowania modułów [N] — mogą jedynie je zaostrzać. Próba wdrożenia policy osłabiającej baseline: automatycznie odrzucana przez OPA gate, alert do SYLION security team.

120.6 Dedicated vs pooled components

Status: [R] Rekomendowany Odbiorca: Architekt | Sales | Infra Wpływ na baseline: Wysoki Powiązane rozdziały: 109.8, 112.4, 120.2

Decyzja o dedykowanych vs współdzielonych komponentach zależy od tieru, wymagań bezpieczeństwa i kosztów.

Matryca dedykacji per tier.

Komponent	STANDARD	PRO	STATE
G1 gateway	Shared (multi-tenant)	Shared (z network isolation)	Dedicated
G2 gateway	Shared	Dedicated lub shared	Dedicated
MicroVM host	Shared host, isolated microVM	Shared host, isolated microVM	Dedicated host (TEE)
HSM	Shared partition	Dedicated partition	Dedicated device (on-prem option)
Management plane	Shared (Zone 5)	Shared (isolated namespace)	Dedicated
SIEM	Shared (per-tenant labels)	Shared (per-tenant encryption)	Dedicated
Monitoring	Shared	Shared (dedicated dashboards)	Dedicated
Matrix homeserver	Shared (optional)	Dedicated instance	Dedicated (air-gap option)

Kiedy dedicated G1/G2 ma sens. (a) Klient wymaga custom ingress IP (dedicated anycast), (b) klient wymaga custom TLS certificates na G1, (c) klient wymaga audit trail na gateway level (bez commingling z innymi tenantami), (d) regulatory requirement (sector-specific regulation mandating dedicated infrastructure), (e) threat model (adversary capable of cross-tenant attacks at network level).

Cost implication. Dedicated G1: +€200-400/month per gateway (2 for HA). Dedicated G2: +€300-500/month. Dedicated HSM: €5-15K/year. Dedicated SIEM: +€500-1000/month. Total STATE dedicated infrastructure premium: €2000-4000/month over shared equivalent.

120.7 Multi-tenant hardening

Status: [N] Normatywny Odbiorca: Architekt | Infra | SOC Wpływ na baseline: Krytyczny Powiązane rozdziały: 120.2, 120.3, 109.8

Multi-tenant hardening zapewnia, że współdzielona infrastruktura nie staje się wektorem ataku cross-tenant.

Network isolation. (a) Default deny: żaden ruch sieciowy pomiędzy tenantami nie jest dozwolony (Kubernetes NetworkPolicy deny-all inter-namespace, Firecracker jailer no-networking default). (b) Per-tenant VLAN/VXLAN: logical network separation (nawet na shared physical network). (c) IPsec per-operator: każdy operator ma dedykowany tunel IPsec (nie shared tunnel per tenant). (d) Egress filtering: per-tenant egress rules (tenant A nie może osiągnąć wewnętrznych zasobów tenant B). (e) No broadcast: disabled na poziomie Firecracker network (unicast only).

Crypto isolation. (a) Per-tenant encryption keys: unique DEK/KEK per tenant (120.3). (b) Per-operator session keys: unique per session (negotiated via IKEv2). (c) No key reuse: keys nigdy nie są reused between tenants/operators/sessions. (d) Key isolation in HSM: per-tenant key partitions (FIPS 140-3 requires partition isolation in multi-tenant HSM).

Audit separation. (a) Per-tenant audit logs: immutable, per-tenant encrypted. (b) Cross-tenant audit: SYLION platform-level audit separate from tenant audit. (c) Tenant cannot access platform audit (only own logs). (d) SYLION platform admin access to tenant audit: restricted, logged, time-bounded.

Testing. (a) Quarterly cross-tenant attack simulation (pentest targeting tenant isolation). (b) Automated scanning for cross-tenant data leakage. (c) Network scan: no unexpected cross-tenant connectivity. (d) Storage scan: no cross-tenant data access. Results: documented, shared with affected tenants if issues found.

Rozdział 121. Scenariusze branżowe

121.1 Finanse

Status: [R] Rekomendowany Odbiorca: Sales | Compliance | Klient (sektor finansowy) Wpływ na baseline: Wysoki Powiązane rozdziały: 114.1, 117.2, 121.9

Sektor finansowy to kluczowy segment dla SYLION, z rygorystycznymi wymaganiami regulacyjnymi.

DORA compliance. Digital Operational Resilience Act (Regulation 2022/2554) obowiązuje od 17 stycznia 2025. Wpływ na SYLION: (a) ICT risk management: SYLION jako „ICT third-party service provider” musi spełniać wymagania DORA Art. 28-30. (b) Incident reporting: financial entities muszą raportować ICT-related incidents — SYLION musi dostarczać informacje umożliwiające spełnienie tych obowiązków. (c) ICT third-party risk: financial entities muszą zarządzać ryzykiem ICT providers — SYLION musi udostępniać informacje potrzebne do oceny ryzyka (SOC 2, security measures, BCP documentation). (d) Testing: financial entities mogą wymagać testowania odporności SYLION (TLPT — Threat-Led Penetration Testing) — SYLION musi wspierać takie testy.

Financial regulator requirements. KNF (Polska): wytyczne dot. cloud outsourcingu, wymóg notyfikacji, exit plan. BaFin (Niemcy): BAIT/VAIT requirements, MaRisk outsourcing requirements. FCA (UK): operational resilience requirements, outsourcing guidelines.

Use cases. (a) M&A deal rooms: bezpieczna komunikacja pomiędzy stronami transakcji M&A (izolowane środowisko, access control, audit trail, automatic data destruction po zakończeniu transakcji). (b) Trading communication: bezpieczna komunikacja tradingowa (zgodna z MiFID II record-keeping, ale z E2EE — wymaga hybrydowego podejścia: metadata i fakty transakcyjne logged, treść komunikacji encrypted). (c) Client data protection: ochrona danych klientów instytucji finansowej (PII, dane finansowe, szczegóły inwestycji).

121.2 Zdrowie

Status: [R] Rekomendowany Odbiorca: Sales | Compliance | Klient (sektor zdrowia) Wpływ na baseline: Wysoki Powiązane rozdziały: 115.1, 114.1

Sektor zdrowia operuje na danych wrażliwych (special categories under GDPR Art. 9) z dedykowanymi regulacjami.

GDPR special categories. Dane zdrowotne (health data) to „special categories of personal data” (Art. 9 GDPR): (a) processing wymaga explicit consent lub specific legal basis (Art. 9(2)), (b) DPIA mandatory (Art. 35(3)(b) — processing on a large scale of special categories), (c) enhanced security measures required. SYLION approach: E2EE zapewnia, że SYLION nie przetwarza (nie ma dostępu do) treści zawierających dane zdrowotne. SYLION przetwarza jedynie metadata (kto się komunikował, kiedy, skąd).

HIPAA (US context). Jeśli klient health sector obsługuje US patients: HIPAA (Health Insurance Portability and Accountability Act) wymaga: (a) Business Associate Agreement (BAA) z SYLION, (b) encryption at rest i in transit (✓ — SYLION default), (c) access controls (✓ — RBAC + FIDO2), (d) audit trail (✓ — Zone 4 logs), (e) breach notification (✓ — 117.6). SYLION US LLC może podpisać BAA.

Telemedicine. SYLION jako platforma telemedyczna: (a) secure video consultation (WebRTC + SFrame E2EE), (b) secure document exchange (CDR sanitized), (c) session recording (opcjonalnie, z informed consent, encrypted, access-controlled), (d) patient identification (operator = lekarz, nie pacjent — pacjent łączy się z lekarzem through external channel, lekarz używa SYLION terminal).

Clinical trial data. Komunikacja związana z badaniami klinicznymi: (a) GCP (Good Clinical Practice) compliance, (b) data integrity (audit trail, immutable logs), (c) separation of concerns (study data separate from operational data), (d) multi-site coordination (secure communication between trial sites).

121.3 Przemysł

Status: [R] Rekomendowany Odbiorca: Sales | Architekt | Klient (sektor przemysłowy) Wpływ na baseline: Średni Powiązane rozdziały: 121.4, 119.1

Sektor przemysłowy stoi przed wyzwaniami konwergencji OT/IT i ochrony własności intelektualnej.

OT/IT convergence. Zbliżanie się sieci operacyjnych (OT) i informatycznych (IT) tworzy nowe wektory ataku. SYLION w kontekście przemysłowym: (a) NOT an OT platform — SYLION nie łączy się bezpośrednio z systemami SCADA/PLC/DCS. (b) Secure communication overlay: SYLION zapewnia bezpieczną komunikację ludzi zarządzających systemami OT (inżynierowie procesowi, operatorzy systemów sterowania, maintenance team). (c) Remote access to documentation: bezpieczny dostęp do dokumentacji technicznej, schematów, procedur — przez remote desktop (nie direct OT access). (d) Incident coordination: bezpieczna komunikacja podczas incydentów OT (separacja od potencjalnie skompromitowanej sieci korporacyjnej).

Industrial espionage protection. SYLION chroni przed szpiegostwem przemysłowym: (a) E2EE uniemożliwia przechwycenie komunikacji (blueprints, patents, trade secrets), (b) CDR sanityzuje dokumenty z ukrytym malware (exfiltration prevention), (c) thin client: żadne dane nie są na urządzeniu końcowym (theft of device ≠ theft of data), (d) IMSI rotation [A]: utrudnia tracking lokalizacji kluczowych pracowników.

Supply chain communication. Bezpieczna komunikacja w łańcuchu dostaw: (a) multi-company SYLION deployment (każda firma jako osobny tenant, cross-tenant komunikacja przez dedykowany bridge), (b) temporary access (project-based operator provisioning z automatycznym wygaśnięciem), (c) document exchange z CDR

(pliki od dostawców sanityzowane przed prezentacją operatorowi).

121.4 Energetyka

Status: [R] Rekomendowany Odbiorca: Sales | Compliance | Klient (sektor energetyczny) Wpływ na baseline: Wysoki Powiązane rozdziały: 114.1, 121.3, 119.1

Energetyka to sektor infrastruktury krytycznej, podlegający NIS2 jako „essential entity”.

NIS2 essential services. Sektor energetyczny (electricity, oil, gas, hydrogen, heating/cooling, district heating) klasyfikowany jako „essential entity” w NIS2: (a) najwyższe wymagania bezpieczeństwa cybernetycznego, (b) nadzór ex-ante (nie ex-post jak dla „important entities”), (c) kary: do €10M lub 2% global turnover. SYLION jako dostawca ICT dla essential entity musi wspierać klienta w spełnieniu wymagań NIS2.

SCADA-adjacent communication. SYLION NIE łączy się z systemami SCADA. Ale komunikacja ludzi zarządzających SCADA korzysta z SYLION: (a) operator dyspozytorni komunikuje się bezpiecznie z maintenance team w terenie, (b) raporty awarii i procedury emergency response przez SYLION (nie przez nieszyfrowany email/telefon), (c) remote access do systemów dokumentacyjnych SCADA (nie do samego SCADA) — przydatne do analizy incydentów, przeglądania logów archiwalnych.

Incident reporting. Obowiązki raportowania incydentów w sektorze energetycznym: (a) NIS2: 24h early warning, 72h notification, 1 month final report do CSIRT, (b) sektorowe (URE w Polsce, BNetzA w Niemczech): dodatkowe wymogi raportowania wg krajowych regulacji, (c) SYLION dostarcza telemetrię i logi umożliwiające klientowi terminowe raportowanie.

Grid security. Bezpieczeństwo sieci energetycznej: (a) ENTSO-E cybersecurity guidelines — SYLION wspiera compliance, (b) emergency communication (blackout scenario): SYLION z Briar fallback [E] umożliwia komunikację nawet przy braku infrastruktury telekomunikacyjnej, (c) cross-border coordination (synchronous grids cross borders): SYLION multi-region enable secure cross-border energy sector communication.

121.5 Media i redakcje

Status: [R] Rekomendowany Odbiorca: Sales | Klient (media/dziennikarze) | PM Wpływ na baseline: Wysoki Powiązane rozdziały: 123.4, 124.4, 121.7

Ochrona źródeł dziennikarskich to fundamentalna wolność w demokracjach. SYLION adresuje ten use case jako kluczowy w Phase 1.

Source protection. Model zagrożeń dla dziennikarza: (a) Adversary: rząd (state actor), korporacja (corporate espionage), organized crime. (b) Attack vectors: communication interception, device seizure, legal compulsion (court orders), social engineering. (c) SYLION protection: E2EE (no content access), thin client (no data on device), IMSI rotation [A] (no location tracking), Briar fallback [E] (communication during internet blackout).

Freedom of Press Foundation alignment. SYLION w kontekście standardów ochrony prasy: (a) SecureDrop: SYLION nie zastępuje SecureDrop (anonymous tip submission), ale uzupełnia go (secure communication after initial contact), (b) EFF surveillance self-defense: SYLION implementuje recommendations z SSD guides, (c) CPJ Digital Safety Kit: SYLION jako narzędzie z toolkitu CPJ.

Hostile state actor threat model. Dziennikarz w autokracji: (a) telefon sklonowany na granicy — thin client: nic na urządzeniu (Pixel z GrapheneOS wyczyszczony, dane w microVM), (b) confiscation — FIDO2 biometric + kill switch, (c) forced unlock — duress mode (fałszywy profil), (d) network surveillance — IPsec + Tor (Dark-Matrix [E]), (e) BTS (fake base station) — IMSI rotation [A].

WAŻNE — USB Kill Switch: Badania University of Warwick (2023) wykazały, że urządzenia USB Kill (wysyłające napięcie zwrotne) niszczą płyty główne, ALE nie niszczą danych na nośnikach SSD/SATA — dyski przetrwały i dane były odzyskiwalne forensycznie. USB Kill NIE jest skuteczną metodą niszczenia danych. Właściwe podejście: Duress PIN GrapheneOS (nieodwracalne zniszczenie kluczy keystore i eSIM), full-disk encryption z Secure Element, auto-reboot do BFU po 18h oraz remote wipe przez management plane.

Device confiscation scenarios. Procedura na wypadek konfiskaty terminala SYLION: (a) operator raportuje utratę (z innego urządzenia lub przez organizację), (b) SYLION natychmiast revokes certyfikat urządzenia (no access to microVM), (c) device wipe via MDM (GrapheneOS remote wipe), (d) microVM operator untouched (dane w cloud, nie na urządzeniu), (e) nowy terminal provisioned (nowy Pixel + router + FIDO2).

121.6 Dyplomacja i misje

Status: [O] Opcjonalny Odbiorca: Sales | Klient (MSZ, ambasady) | CISO Wpływ na baseline: Wysoki Powiązane rozdziały: 119.6, 121.5, 124.3

Komunikacja dyplomatyczna wymaga najwyższych standardów bezpieczeństwa, zbliżonych do STATE tier.

Classified-adjacent communication. SYLION nie jest certyfikowanym systemem kryptograficznym do informacji niejawnych (TAJNE/SECRET). Ale SYLION adresuje komunikację na poziomie „classified-adjacent”: wrażliwe, ale nie formalnie sklasyfikowane rozmowy dyplomatyczne (pre-decisional discussions, negotiation strategies, intelligence-adjacent analysis). Tier STATE z sovereign deployment zapewnia odpowiedni poziom ochrony.

Foreign ministry requirements. (a) Data sovereignty: dane muszą pozostać w jurysdykcji ministerstwa (on-premise deployment w ambasadzie lub sovereign cloud), (b) diplomatic pouch equivalent: digital delivery via encrypted offline media (air-gap capable Matrix), (c) multi-post communication: secure federation between embassy deployments (via dedicated diplomatic network lub Dark-Matrix [E] via Tor), (d) language diversity: UI w wielu językach, support wielojęzyczny.

Hostile territory operations. Ambasada w państwie autorytarnym: (a) local ISP monitored — IPsec + Tor obfuscation (traffic looks normal), (b) IMSI catchers near embassy — IMSI rotation [A], data-only SIMs, (c) physical surveillance — thin client (device confiscation reveals nothing), (d) electromagnetic surveillance — shielded communication room (TEMPEST) + SYLION encryption, (e) internet shutdown — Briar offline fallback [E] (local communication), satellite backup (Starlink + SYLION VPN).

Evacuation procedures. W sytuacji ewakuacji: (a) emergency wipe all terminals (remote command from HQ), (b) HSM zeroization (on-premise HSM self-destructs on trigger), (c) evidence destruction (crypto-shredding: delete encryption keys, data becomes unrecoverable), (d) communication continuity: pre-provisioned backup terminals w innym deployment (HQ lub friendly embassy).

121.7 NGO high-risk

Status: [R] Rekomendowany Odbiorca: Sales | PM | Klient (NGO) Wpływ na baseline: Wysoki Powiązane rozdziały: 121.5, 124.4, 123.4

NGOs działające w wrogim środowisku (autorytarne państwa, strefy konfliktu) to core target Phase 1 SYLION.

Hostile state threat model. Adversary: państwo z rozbudowanymi zdolnościami cyber (Rosja, Chiny, Iran, Arabia Saudyjska, ZEA — bez publicznego wskazywania w dokumentach sprzedażowych). Capabilities: (a) passive interception (all ISP traffic), (b) active attacks (MITM, fake base stations), (c) legal compulsion (seize devices, compel cooperation of local telcos), (d) physical surveillance (track phones, GPS, camera), (e) social engineering (infiltrate organization).

Field team safety. (a) Thin client: urządzenie skonfiskowane nie ujawnia danych. (b) Duress mode: fałszywy profil na wypadek wymuszenia odblokowania. (c) No-data-on-terminal: wyczyszczone urządzenie → microVM w bezpiecznej jurysdykcji. (d) IMSI rotation [A]: utrudnienie śledzenia lokalizacji. (e) Kill switch: emergency remote wipe.

Budget constraints. NGOs mają ograniczone budżety. SYLION approach: (a) NGO pricing program (dyskretny — nie publikowany, aby nie dewaluować commercial pricing), (b) hardware kit cost reduction: refurbished Pixel, open-source router, (c) STANDARD tier z selected security add-ons (zamiast full PRO), (d) grant funding support (pomoc w uzyskaniu grantów na cyberbezpieczeństwo — Digital Defenders Partnership, OTF, Google.org).

Offline fallback (Briar [E]). Internet blackout scenarios (autorytarny reżim wyłącza internet podczas protestów): (a) Briar P2P mesh (Bluetooth + WiFi Direct), (b) separate profile na GrapheneOS (izolowany od SYLION main app), (c) message propagation through mesh network, (d) reference: Hong Kong 2019, Myanmar 2021, Iran 2022 internet shutdowns. Limitation: Android only (no iOS Briar client), short range (Bluetooth ~10m, WiFi Direct ~100m).

Training non-technical users. NGO operatorzy to często ludzie bez background techniczny: (a) onboarding w 30 minut (prosty wizard), (b) visual guides (nie tekst-heavy manuals), (c) local language support (nie tylko EN), (d) train-the-trainer model (1 technical person per NGO team), (e) emergency contact card (co robić: urządzenie skonfiskowane, internet wyłączony, podejrzenie surveillance).

121.8 Obrona i public safety

Status: [O] Opcjonalny Odbiorca: Sales | CISO | Legal Wpływ na baseline: Krytyczny Powiązane rozdziały: 119.1, 116.5, 116.6

Sektor obronny to Phase 2 target, wymagający certyfikacji (CC, FedRAMP, FIPS).

Defense contractor communication. Firmy zbrojeniowe (Lockheed Martin, Rheinmetall, PGZ) wymagają: (a) CUI protection (Controlled Unclassified Information — NIST SP 800-171), (b) CMMC 2.0 compliance (Cybersecurity Maturity Model Certification — US requirement for defense contractors), (c) no-CLOUD Act: dane defense contractor nie mogą podlegać CLOUD Act jurisdiction → SYLION Swiss AG jako controller, data residency w CH/EU. (d) Supply chain security: SYLION musi ujawnić supply chain (software BOM, hardware origin, third-party components).

Compartmented information. SYLION nie obsługuje informacji sklasyfikowanych (TAJNE/SECRET/TOP SECRET), ale wspiera „compartmented” approach dla information unclassified but sensitive: (a) project-based compartments: grupy operatorów z dostępem wyłącznie do swojego projektu, (b) no cross-compartment communication (policy-enforced), (c) audit trail per compartment, (d) automatic declassification schedule.

National security consideration. Używanie foreign-origin secure communication platform przez krajowe siły zbrojne wymaga: (a) national security assessment (czy platforma może być backdoored?), (b) source code review (STATE tier provides under NDA), (c) independent cryptographic evaluation, (d) sovereign deployment (dane w krajowej jurysdykcji, klucze pod kontrolą narodową). SYLION architecture supports all requirements.

121.9 Centrala korporacyjna i M&A

Status: [R] Rekomendowany Odbiorca: Sales | Klient (C-suite) | PM Wpływ na baseline: Średni Powiązane rozdziały: 121.1, 120.1, 117.2

Komunikacja zarządu i procesów M&A wymaga izolacji od potencjalnie skompromitowanej sieci korporacyjnej.

Board communication security. (a) Dedicated SYLION environment for board members (separate tenant lub isolated compartment), (b) enhanced FIDO2 (biometric + PIN, no fallback), (c) limited operator count (10-20 board members + support staff), (d) extended audit (all access logged, immutable, reviewed quarterly), (e) content never touches corporate network (thin client: board member accesses corporate documents through SYLION remote desktop, not through corporate laptop).

M&A war room. Transakcja M&A to najwyższej wartości informacja w biznesie: (a) temporary dedicated environment (provisioned for deal, destroyed after), (b) strict access control (need-to-know, per-workstream), (c) no data on devices (all documents in microVM, accessed via remote desktop), (d) document watermarking [E] (micro-watermark identifies leaker if document leaked), (e) time-limited access (automatic expiry after deal close), (f) legal hold capability (preserve all communication for regulatory review if required).

Executive protection. C-suite executives jako targets: (a) personal device isolation (SYLION Pixel separate from corporate phone), (b) travel security (IMSI rotation [A], clean device for border crossing, data-only SIM), (c) anti-surveillance (location tracking resistance via IMSI rotation + VPN), (d) emergency communication (out-of-band channel if corporate network compromised).

121.10 SOC/CSIRT operations

Status: [R] Rekomendowany Odbiorca: SOC | CISO | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 119.4, 121.8

SOC i CSIRT teams potrzebują bezpiecznej komunikacji niezależnej od potencjalnie skompromitowanej infrastruktury korporacyjnej.

Separation from compromised infrastructure. W trakcie incydentu: (a) korporacyjna sieć (email, Slack, Teams) może być skompromitowana, (b) adversary może monitorować komunikację incident response team, (c) SYLION jako out-of-band communication: oddzielna infrastruktura, oddzielne urządzenia, oddzielne credentials. (d) Best practice: SOC team ma SYLION terminals permanently provisioned (nie dopiero w trakcie incydentu — then it's too late to set up).

Incident response communication. (a) Dedicated SYLION environment for IR team (isolated tenant), (b) pre-configured channels: IR leadership, technical team, legal team, external communications, (c) evidence sharing through SYLION (CDR-sanitized, encrypted, access-controlled), (d) external communication: with law enforcement, CERT teams, affected parties — through SYLION (not through compromised email).

Use case: assume breach. Scenario: corporate network fully compromised by sophisticated adversary (APT): (a) All corporate communication assumed monitored, (b) IR team switches to SYLION (separate devices, separate network), (c) Investigation coordinated through SYLION, (d) Evidence collected and shared through

SYLION (not corporate file shares), (e) Communication with management through SYLION (board members with SYLION access — 121.9). SYLION = secure fallback communication that adversary cannot compromise (different infrastructure, different attack surface, no shared credentials with corporate).

Rozdział 122. Rozszerzenia AI, edge i federacyjne [O/E]

122.1 Edge AI — lokalna inferencja dla detekcji anomalii

Status: [E] Eksperymentalny Odbiorca: Architekt | SOC | R&D Wpływ na baseline: Niski Powiązane rozdziały: 122.2, 122.4, 122.6

Edge AI oznacza uruchomienie modeli inferencyjnych lokalnie (na terminalu operatora lub routerze dostępowym), bez konieczności wysyłania danych do cloud.

Use case: anomaly detection. Lokalne modele wykrywające anomalie na terminalu: (a) nietypowe wzorce ruchu sieciowego (np. exfiltration attempt z microVM), (b) nietypowe zachowanie interfejsu (np. automated input suggesting compromised remote desktop), (c) environmental anomalies (np. new BTS detected — potential IMSI catcher). Model trained centrally, deployed to edge, inference local — no data sent to cloud for analysis.

Technical approach. (a) Lightweight models: TensorFlow Lite / ONNX Runtime na Pixel (ARM), (b) model size: <50MB (fit in terminal storage), (c) inference time: <100ms (real-time detection), (d) model update: signed model updates delivered through SYLION update channel (no unauthorized model replacement), (e) privacy: raw data stays on device, only alerts (binary: anomaly/normal + confidence score) sent to SOC.

Security considerations. (a) Adversarial attacks: model evasion (adversary crafts inputs to avoid detection) — mitigated by ensemble models + periodic model rotation. (b) Model poisoning: if model update channel compromised, adversary could deploy blind model — mitigated by model signing (ML-DSA-87) + model validation on device. (c) Privacy: model inference must not reveal operator behavior patterns to SYLION (local-only inference).

Limitations. (a) Limited compute on Pixel (no GPU inference, CPU only), (b) battery impact (continuous inference drains battery — must be duty-cycled), (c) false positive rate (lightweight models less accurate than cloud models — tuning required), (d) update latency (model updates not real-time — days between model pushes).

122.2 Federated learning

Status: [E] Eksperymentalny Odbiorca: R&D | Architekt Wpływ na baseline: Niski Powiązane rozdziały: 122.1, 122.4

Federated learning (FL) umożliwia trenowanie modeli ML na danych wielu tenantów bez centralizacji danych.

Concept. Zamiast zbierać dane od tenantów do centralnego modelu: (a) SYLION dystrybuje model do tenantów, (b) każdy tenant trenuje model lokalnie na swoich danych (w swoim cluster), (c) tenant odsyła gradient updates (nie raw data) do aggregation server, (d) aggregation server uśrednia gradienty (Federated Averaging), (e) nowy global model dystrybuowany do tenantów.

Use cases. (a) Threat detection: model wykrywający nowe attack patterns, trenowany na danych wielu tenantów (zbiorowa inteligencja) bez ujawniania danych między tenantami. (b) Anomaly baseline: model normalnego zachowania systemu, trenowany across tenants (diversified normal = better baseline). (c) CDR effectiveness: model classifying suspicious files, trained on CDR decisions across tenants.

Privacy-preserving ML. (a) Differential privacy: noise addition to gradient updates (ϵ -differential privacy guarantee), (b) secure aggregation: gradient updates encrypted in transit (MPC or HE-based aggregation), (c) minimum tenant count: FL effective only with 10+ tenants, (d) opt-in: tenants must explicitly opt into FL (not default).

Limitations. (a) Communication overhead (gradient exchanges), (b) non-IID data (tenants have different distributions — convergence issues), (c) free-rider problem (tenant benefits from global model without contributing meaningful updates), (d) Byzantine resilience (malicious tenant could poison global model — requires robust aggregation).

122.3 Local inference na terminalu

Status: [E] Eksperymentalny Odbiorca: R&D | PM Wpływ na baseline: Niski Powiązane rozdziały: 122.1, 122.4

Lokalna inferencja (on-device models) na terminalu Pixel wykraczająca poza anomaly detection.

Potential applications. (a) Smart keyboard prediction (encrypted, local-only, no data sent to cloud), (b) document classification (categorize documents viewed in remote desktop by sensitivity), (c) voice activity detection (optimize audio stream by detecting speech vs silence locally), (d) OCR for scanned documents (local extraction, no cloud OCR exposure).

Technical constraints. Pixel 8/9 z Tensor G3/G4: (a) Neural processing unit (NPU/TPU): available for TFLite models, (b) 8-12 GB RAM: constraints on model size (must fit in memory alongside GrapheneOS + SYLION client), (c) battery: continuous inference not feasible, event-triggered preferred, (d) storage: model + data must fit in available storage (no SD card in Pixel). Realistic model budget: 100-200 MB models, <500ms inference.

Privacy guarantees. Local inference must guarantee: (a) no model output sent to SYLION (stays on device unless operator explicitly shares), (b) no training data collected from device (inference-only, no fine-tuning on device that could memorize operator data), (c) model does not contain encoded information about other operators/tenants (trained with differential privacy).

122.4 Sensitive data governance for AI

Status: [N] Normatywny Odbiorca: R&D | Compliance | CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 122.1–122.3, 115.1

Governance danych wrażliwych w kontekście AI jest krytyczny — naruszenie może podważyć fundamenty prywatności SYLION.

Zasada fundamentalna: treść komunikacji NIGDY nie jest używana do trenowania modeli. E2EE gwarantuje technicznie, że SYLION nie ma dostępu do treści. Ale nawet metadata (timing, volume, frequency) musi być traktowane ostrożnie.

Co MOŻE być użyte do ML. (a) Platform-level metrics: CPU utilization, memory usage, network throughput (aggregated, per-component, not per-operator). (b) Security telemetry: failed login attempts, anomaly scores, CDR decisions (file blocked/passed) — without file content. (c) Infrastructure metrics: server health,

network latency, storage performance. (d) Anonymized aggregate patterns: „80% sessions last 30-60 minutes” — bez identyfikacji konkretnego operatora.

Co NIE MOŻE być użyte do ML. (a) Communication content (impossible due to E2EE, but policy reinforces). (b) Per-operator behavior (session times, communication partners, frequency) without explicit opt-in. (c) Operator identifiers (even hashed) in training data without consent. (d) Cross-tenant data without both tenants’ explicit opt-in (FL requirement).

Regulatory alignment. (a) GDPR: machine learning on personal data = processing → requires legal basis (Art. 6). Legitimate interest possible for security AI, but requires DPIA. (b) EU AI Act: SYLION AI features classified based on risk level. Anomaly detection = limited risk (transparency obligation). No high-risk AI use cases in SYLION (no biometric identification, no social scoring). (c) Automated decision-making (Art. 22 GDPR): if AI decisions affect operators (e.g., account lockout), right to human review applies.

122.5 Security implications

Status: [R] Rekomendowany Odbiorca: CISO | Architekt | R&D Wpływ na baseline: Wysoki Powiązane rozdziały: 122.1–122.4

Integracja AI/ML wprowadza nowe wektory ataku, które muszą być adresowane.

Adversarial attacks. (a) Evasion: adversary modyfikuje input aby uniknąć detekcji (np. exfiltration traffic shaped to look normal). Mitigation: ensemble models, regular retraining, anomaly detection na anomaly detector (meta-detection). (b) Poisoning: adversary infects training data (especially in federated learning). Mitigation: robust aggregation (Byzantine-resilient FL), training data validation, anomaly detection na gradient updates. (c) Model extraction: adversary queries model repeatedly to reconstruct it. Mitigation: rate limiting queries, differential privacy, not exposing prediction confidence.

Prompt injection. Jeśli SYLION integrates LLM-based features (np. smart document analysis): (a) prompt injection via documents (malicious document with embedded instructions for LLM), (b) mitigation: sandboxed LLM inference, output validation, no LLM access to system operations, (c) policy: LLM features classified as [E], not in certifiable core.

Data poisoning. (a) Compromised tenant in FL could poison global model → impacts all tenants. (b) Mitigation: contribution validation, anomaly detection on gradient updates, robust aggregation (trimmed mean, Krum), ability to exclude suspicious tenants from FL. (c) Emergency: if poisoning detected, rollback global model to last known-good version.

122.6 Operational implications

Status: [R] Rekomendowany Odbiorca: Infra | SOC | R&D Wpływ na baseline: Średni Powiązane rozdziały: 122.1–122.5

Operacyjne aspekty wdrożenia AI/ML w SYLION.

Model updates. (a) Signed model artifacts (ML-DSA-87 signature), (b) staged rollout (canary → 10% → 50% → 100%), (c) rollback capability (previous model version retained), (d) validation gates: new model must pass accuracy/precision/recall thresholds before rollout, (e) model registry: versioned models with lineage tracking (which data, which training run, which hyperparameters).

Validation. (a) Pre-deployment: test dataset validation (accuracy, false positive rate, bias detection), (b) Post-deployment: continuous monitoring of model performance (drift detection), (c) A/B testing: new model vs old model on subset of traffic, (d) Human review: security team reviews model decisions weekly (sample of alerts).

Monitoring. (a) Model performance metrics: accuracy, precision, recall, F1 score — tracked over time. (b) Drift detection: data distribution shift → alert (model may need retraining). (c) Latency monitoring: model inference time (must stay within SLA). (d) Resource monitoring: CPU/GPU utilization by AI workloads. (e) Alert fatigue monitoring: if false positive rate increases, tune or retrain.

Rozdział 123. Moduły autonomiczne [A]

123.1 Definicja modułów autonomicznych

Status: [N] Normatywny Odbiorca: Wszyscy Wpływ na baseline: Krytyczny Powiązane rozdziały: 123.2, 123.9, 117.9

Moduł autonomiczny [A] to komponent systemu SYLION, który: (a) znajduje się poza certyfikowalnym rdzeniem platformy, (b) odpowiedzialność za jego użycie spoczywa na operatorze i organizacji klienta (nie na SYLION), (c) jego legalność zależy od jurysdykcji (legal w jednej, illegal w innej), (d) nie jest częścią standardowego instalatora — wymaga odrębnej aktywacji.

Dlaczego moduły autonomiczne istnieją. Pewne funkcjonalności (np. IMSI rotation, jurisdictional hopping) dostarczają realną wartość bezpieczeństwa dla określonych grup operatorów (dziennikarze, aktywiści, dyplomaci), ale: (a) ich legalność jest zróżnicowana jurysdykcyjnie, (b) ich włączenie do certyfikowalnego rdzenia uniemożliwiłoby certyfikację (ISO 27001, SOC 2, Common Criteria, FedRAMP), (c) ich nieprawidłowe użycie mogłoby narazić SYLION na odpowiedzialność prawną. Dlatego istnieją jako odrębna kategoria z formalnym procesem aktywacji i transferem odpowiedzialności.

Lista modułów [A].

Moduł	Legalność	Ryzyko
IMSI/eSIM rotation	LEGAL (EU/US/CH)	Niskie
IMEI modification	ILLEGAL (EU/UK +16 krajów)	KRYTYCZNE
BTS forcing	Szara strefa (ToS violation)	Wysokie
Jurisdictional hopping	Legal, ale risk-laden	Wysokie
Hardware experiments	Zależy od konkretnego eksperymentu	Średnie-Wysokie

Activation process. (a) Customer request (formal, written), (b) SYLION legal review (per-jurisdiction), (c) Risk acknowledgment form signed by customer, (d) Technical enablement (separate installation, separate update channel), (e) Documentation of module scope and limitations, (f) Annual review of continued use.

123.2 Granice odpowiedzialności

Status: [N] Normatywny Odbiorca: Legal | Klient | Sales Wpływ na baseline: Krytyczny Powiązane rozdziały: 123.1, 117.4, 117.9

Podział odpowiedzialności pomiędzy SYLION a klientem w kontekście modułów autonomicznych musi być absolutnie jednoznaczny.

SYLION odpowiada za: (a) dostarczenie dokumentacji technicznej modułu, (b) udokumentowanie known risks i ograniczeń, (c) udokumentowanie statusu prawnego modułu w znanych jurysdykcjach, (d) zapewnienie, że moduł [A] nie osłabia rdzenia certyfikowalnego (123.3), (e) security updates modułu (best-effort, nie SLA-guaranteed), (f) clear labeling modułu jako [A] we wszystkich interfejsach i dokumentacji.

Klient (organizacja) odpowiada za: (a) weryfikację legalności modułu w swojej jurysdykcji (z niezależną opinią prawną), (b) decyzję o aktywacji modułu, (c) szkolenie operatorów w zakresie modułu, (d) monitoring użycia modułu, (e) konsekwencje prawne wynikające z użycia modułu, (f) incydenty operacyjne wynikające z modułu (SLA nie obejmuje [A]).

Operator odpowiada za: (a) prawidłowe użycie modułu zgodnie z dokumentacją, (b) compliance z lokalnymi przepisami prawa, (c) raportowanie problemów do organizacji.

Kontraktowe zabezpieczenie SYLION. Umowa z klientem używającym modułów [A] zawiera: (a) indemnification clause (klient zwalnia SYLION z odpowiedzialności za konsekwencje użycia modułów [A]), (b) hold harmless clause (klient zobowiązuje się nie kierować roszczeń wobec SYLION), (c) jurisdiction-specific waiver (klient potwierdza, że zweryfikował legalność w swojej jurysdykcji).

123.3 Wymagania wobec rdzenia przy współpracy z modułem autonomicznym

Status: [N] Normatywny Odbiorca: Architekt | CISO Wpływ na baseline: Krytyczny Powiązane rozdziały: 123.1, 123.2

Fundamentalna zasada: moduł autonomiczny [A] NIGDY nie może osłabić bezpieczeństwa rdzenia certyfikowalnego.

Isolation requirements. (a) Process isolation: moduł [A] działa w odrębnym procesie/kontenerze/microVM (nie w tym samym procesie co rdzeń). (b) Network isolation: moduł [A] nie ma dostępu do wewnętrznych API rdzenia (komunikacja wyłącznie przez zdefiniowane, audytowane interfejsy). (c) Privilege isolation: moduł [A] nie ma uprawnień do modyfikacji konfiguracji rdzenia. (d) Data isolation: moduł [A] nie ma dostępu do kluczy kryptograficznych rdzenia (HSM partitions separated).

Integration requirements. (a) Well-defined API: moduł [A] komunikuje się z rdzeniem wyłącznie przez udokumentowane API (OpenAPI contract). (b) Input validation: rdzeń waliduje wszystkie dane od modułu [A] (treat as untrusted input). (c) Fail-safe: jeśli moduł [A] zawiedzie, rdzeń kontynuuje normalną pracę (graceful degradation). (d) Audit: wszystkie interakcje modułu [A] z rdzeniem logowane w Zone 4 (audit trail).

Certification boundary. Certyfikowalny rdzeń SYLION (ISO 27001, SOC 2, CC, FedRAMP) explicitly excludes moduły [A] ze scope. Dokumentacja certyfikacyjna (SoA, Security Target, SSP) jasno definiuje boundary: „The following modules are out of scope: [list of A modules]. These modules operate in isolation from the certified core and do not affect the security properties of the certified system.”

123.4 Rotacja IMSI/eSIM

Status: [A] Autonomiczny Odbiorca: Operator | Klient | CISO Wpływ na baseline: Niski (nie wpływa na rdzeń) Powiązane rozdziały: 123.1, 123.5, 121.5

STATUS PRAWNY: LEGALNE. Rotacja IMSI (International Mobile Subscriber Identity) jest legalna — oferowana komercyjnie przez operatorów MVNO (Cape, Silent Link, podobni). Użytkownik zmienia profil SIM/eSIM, uzyskując nowy IMSI z puli operatora MVNO.

Jak to działa. (a) Cape (MVNO) oferuje usługę rotacji IMSI: karta eSIM z możliwością programatycznej zmiany IMSI (nowy numer abonenta w sieci mobilnej). (b) Rotacja może być: manualna (operator inicjuje przez aplikację), automatyczna (scheduled — np. co 24h), event-triggered (np. po wykryciu nowej stacji BTS w pobliżu). (c) Technicznie: Cape API → eSIM profile download → new IMSI active → old IMSI deactivated.

Co chroni. (a) Tower dump correlation: policja zbiera listę IMSI widocznych na danej stacji BTS w danym czasie. Rotacja IMSI sprawia, że operator nie pojawia się na liście z tym samym identyfikatorem dwa razy. (b) IMSI catcher (Stingray/fake BTS): device forcing IMSI disclosure — ale zrotowany IMSI nie da się powiązać z tożsamością operatora (MVNO nie udostępnia danych bez court order w swojej jurysdykcji). (c) Location tracking over time: ciągłe śledzenie operatora na podstawie IMSI jest utrudnione (IMSI zmienia się).

Ograniczenia. (a) EID (Embedded Identity Document) — identyfikator eSIM — jest persistent i nie zmienia się przy rotacji IMSI. Jeśli adversary ma dostęp do EID (np. z operatora sieci), rotacja IMSI jest mniej skuteczna. (b) IMEI: identyfikator urządzenia (nie SIM) — nie zmienia się przy rotacji IMSI. Device fingerprinting nadal możliwy (ale patrz: IMEI modification — 123.9, ILLEGAL). (c) Network behavior fingerprinting: wzorec połączeń, timing, app traffic — persistent nawet przy nowym IMSI.

Implementacja w SYLION. (a) Integracja z Cape API (lub podobnym MVNO), (b) automatyczna rotacja IMSI configurable per operator, (c) minimum: rotacja co 24h (rekomendowane: co 12h lub częściej w high-threat environment), (d) koszt: wliczony w subscription Cape MVNO (~€10-20/month per SIM).

123.5 Maskowanie telekomunikacyjne

Status: [A] Autonomiczny Odbiorca: Operator | CISO Wpływ na baseline: Niski Powiązane rozdziały: 123.4, 123.6

Maskowanie telekomunikacyjne to kombinacja technik utrudniających identyfikację operatora przez sieć komórkową.

Składniki. (a) IMSI rotation (123.4) — zmiana tożsamości abonenta. (b) Data-only SIM: SIM bez rejestracji głosowej (no voice registration = no link to real identity via phone number). (c) No voice calls: SYLION communication wyłącznie przez encrypted data (VoIP over IPsec, not GSM voice) — brak rejestracji połączeń głosowych w logach operatora sieci. (d) Prepaid data SIM (anonymous purchase where legal): SIM zakupiony bez ID verification (legal w wielu jurysdykcjach EU, illegal w kilku — np. Niemcy wymagają ID).

Benefits. (a) Tower dump: IMSI rotated + data-only SIM = operator nie widoczny jako „osoba z numerem telefonu” na liście stacji BTS, lecz jako „anonymous data session”. (b) CDR (Call Detail Records u operatora telco): brak voice calls → brak CDR zawierających numery docelowe. (c) Billing correlation: prepaid data SIM paid cash or crypto → no billing record linked to identity.

Limitations. (a) IMEI persistent (urządzenie identyfikowalne, chyba że [A] IMEI modification — ILLEGAL). (b) Network behavior: traffic patterns (timing, volume, destinations) persistent. (c) Physical surveillance: maskowanie telekomunikacyjne nie chroni przed fizycznym śledzeniem. (d) Lawful interception: jeśli operator sieci współpracuje z organami ścigania, może redirectować traffic (ale SYLION IPsec encryption makes content unreadable).

Maskowanie ≠ anonimowość. Maskowanie telekomunikacyjne utrudnia masową inwigilację (tower dumps, IMSI catchers), ale nie zapewnia pełnej anonimowości wobec zdeterminowanego, zasobnego adversary (state actor z współpracą telco + physical surveillance + traffic analysis).

123.6 Wymuszanie dalekich BTS

Status: [A] Autonomiczny Odbiorca: Operator | CISO | R&D Wpływ na baseline: Niski Powiązane rozdziały: 123.4, 123.5

Wymuszanie połączenia z odległą stacją bazową (BTS forcing) ma na celu utrudnienie triangulacji lokalizacji.

Koncept. Telefon normalnie łączy się z najbliższą (najsilniejszą) stacją BTS. Wymuszenie połączenia z odleglejszą BTS sprawia, że triangulacja (ustalenie lokalizacji na podstawie sygnałów z wielu BTS) daje błędny wynik — operator wydaje się być w innym miejscu.

Implementacja techniczna. (a) Modem AT commands: na poziomie modemu (baseband) możliwe jest: wymuszenie konkretnego LAC (Location Area Code), black-listing bliskich BTS, preferowanie dalekich BTS. (b) Pixel z GrapheneOS: ograniczony dostęp do modem AT commands (baseband isolation — security feature GrapheneOS). (c) Alternative: external modem (USB modem with AT command access) connected to GL-iNet router.

Legal considerations. (a) Nie jest to nielegalne per se (użytkownik kontroluje swoje urządzenie), ale: (b) naruszenie ToS operatora sieci (operator może disconnect), (c) zakłócenie sieci: wymuszenie połączenia z odległym BTS może powodować zakłócenia (unlikely w praktyce, ale theoretical risk), (d) gray area: nie ma explicit law prohibiting, ale nie ma explicit law permitting. Klasyfikacja: [A] — użycie na własne ryzyko operatora.

Effectiveness. Ograniczona: (a) triangulacja wymaga sygnałów z 3+ BTS — forcing jednego BTS nie eliminuje triangulacji z pozostałych, (b) timing advance: even forced BTS reveals approximate distance (physics-based), (c) network-level: operator sieci widzi forced connection i może to zignorować lub raportować, (d) sophisticated adversary: traffic analysis + timing = localization mimo BTS forcing.

Rekomendacja. BTS forcing jako samodzielna technika jest mało skuteczne. W połączeniu z IMSI rotation + data-only SIM: dodaje marginalną wartość. SYLION nie rekomenduje jako primary protection — lepsze rozwiązanie: unikanie phone/data connection w high-risk situation (airplane mode + Briar [E]).

123.7 Jurisdictional hopping

Status: [A] Autonomiczny Odbiorca: Architekt | Legal | CISO Wpływ na baseline: Niski Powiązane rozdziały: 110.5, 114.8, 123.1

Jurisdictional hopping polega na routowaniu ruchu przez wiele jurysdykcji, aby skomplikować proces prawny (legal process) wymagany do uzyskania dostępu do danych.

Koncept. Zamiast routować traffic bezpośrednio: Operator → G1 (jurysdykcja A) → G2 (jurysdykcja A) → MicroVM (jurysdykcja A), routing przechodzi przez wiele jurysdykcji: Operator → G1 (Szwajcaria) → G2 (Islandia) → MicroVM (Panama). Efekt: organ ścigania z jednej jurysdykcji musi uzyskać MLAT (Mutual Legal Assistance Treaty) z wieloma jurysdykcjami, co wydłuża proces o miesiące/lata.

Infrastructure design. (a) Multi-region deployment z nodes w strategicznych jurysdykcjach: Szwajcaria (silna ochrona prywatności), Islandia (wolność prasy, strong data protection), Holandia (liberal telecom laws), Singapur (nie-US, nie-EU), Panama (limited MLAT coverage). (b) Routing rules: configurable per operator (organizacja klienta wybiera routing path). (c) No single jurisdiction has complete picture: G1 zna source IP, G2 zna target MicroVM, ale żaden node nie zna obu.

Legal risk analysis. (a) Samo jurisdictional hopping jest legalne — firmy routują traffic międzynarodowo z wielu powodów (performance, reliability, compliance). (b) Ale: jeśli cel jest „obstruction of justice” (celowe utrudnianie legal process), może być traktowane negatywnie przez sądy. (c) SYLION dokumentuje jurisdictional hopping jako feature „data residency optimization” i „network resilience”, nie jako „obstruction of legal process”. (d) Customer responsibility: klient decyduje o routing, SYLION provides capability.

When appropriate. (a) Journalists in hostile states (MLAT pomiędzy hostile state a Szwajcarią nie będzie użyty do prześladowania dziennikarza). (b) NGOs targeted by authoritarian governments. (c) Legal privilege protection (law firm routing through Switzerland for Swiss privacy protection). (d) NOT appropriate for: criminal evasion (AUP violation — 117.3), tax evasion, sanctions circumvention.

123.8 Hardware experiments

Status: [A] Autonomiczny + [E] Eksperymentalny Odbiorca: R&D | Architekt Wpływ na baseline: Niski Powiązane rozdziały: 123.1, 124.6

Eksperymenty sprzętowe obejmują modyfikacje hardware poza standardowym kit SYLION.

Custom router firmware. (a) GL-iNet routery z OpenWrt: custom firmware z dodatkowymi security features (packet inspection, traffic shaping, anomaly detection on router). (b) Risk: custom firmware nie przechodzi standard GL-iNet security updates → klient odpowiada za patching. (c) Classification: [A] — poza standardowym kit, na ryzyko klienta.

Hardware security modules below HSM grade. (a) YubiHSM 2 (~€600): budget-friendly HSM for STANDARD/PRO (nie FIPS 140-3 Level 3, ale FIPS 140-2 Level 2). (b) Nitrokey HSM 2: open-hardware HSM. (c) TPM-based key storage: leveraging Pixel's Titan M2 chip for key protection (beyond standard FIDO2 use). (d) Classification: [A] — nie walidowane na tym samym poziomie co production HSM.

Experimental TEE hardware. (a) RISC-V with custom TEE (Keystone, Sanctum): open-source TEE alternative to AMD SEV-SNP/Intel TDX. (b) ARM TrustZone experiments: leveraging Pixel's TrustZone for additional isolation. (c) FPGA-based crypto accelerators: custom FPGA for PQC operations (experimental, not validated). (d) Classification: [A] + [E] — experimental hardware with autonomous deployment.

Risk management. Hardware experiments [A]+[E] podlegają najsurowszemu reżimowi: (a) separate from production (never on production infrastructure), (b) no customer data (synthetic test data only), (c) no network connectivity to production (air-gapped lab), (d) results reviewed by CISO before any production consideration.

123.9 Ryzyka prawne i operacyjne

Status: [N] Normatywny Odbiorca: Legal | Klient | Wszyscy Wpływ na baseline: Krytyczny Powiązane rozdziały: 123.1–123.8, 117.9

⚠️ OSTRZEŻENIE: MODYFIKACJA IMEI JEST NIELEGALNA ⚠️

Zmiana IMEI (International Mobile Equipment Identity) urządzenia jest przestępstwem w: Unii Europejskiej, Wielkiej Brytanii, Indiach, Australii oraz co najmniej 16 innych jurysdykcjach. Kary obejmują: grzywnę, konfiskatę sprzętu, karę pozbawienia wolności (w zależności od jurysdykcji).

SYLION explicite NIE OFERUJE modyfikacji IMEI. Dokumentacja modułów [A] opisuje IMEI modification wyłącznie w kontekście ostrzegawczym — aby operatorzy rozumieli, że: (a) jest to nielegalne, (b) SYLION nie dostarcza narzędzi do IMEI modification, (c) samodzielna modyfikacja IMEI powoduje utratę wszelkiego wsparcia SYLION, (d) klient używający IMEI modification narusza AUP i umowę.

Ryzyka prawne modułów [A] — ogólne. (a) IMSI rotation: niskie ryzyko (legalne, komercyjnie oferowane), ale: (a1) klient musi zweryfikować legalność w swojej konkretnej jurysdykcji, (a2) w niektórych krajach prepaid SIM registration mandatory → anonymous SIM illegal. (b) BTS forcing: gray area — naruszenie ToS operatora, potencjalnie zakłócenie sieci (telco law violation). (c) Jurisdictional hopping: legalne per se, ale może być kwestionowane jako obstruction of justice. (d) Hardware experiments: zależy od konkretnego eksperymentu — modyfikacja radiowego hardware może naruszać radio frequency regulations.

Ryzyka operacyjne. (a) Moduły [A] nie objęte SLA → downtime nie kompensowany. (b) Security updates best-effort → vulnerabilities may persist. (c) Integration issues → moduł [A] może zakłócić user experience (np. IMSI rotation powoduje krótki disconnect). (d) Support limitations → L1/L2 support nie obejmuje modułów [A].

123.10 Jak dokumentować odstępstwa autonomiczne

Status: [N] Normatywny Odbiorca: Compliance | Legal | Klient Wpływ na baseline: Wysoki Powiązane rozdziały: 123.1, 129.6, 117.9

Formalna dokumentacja jest obowiązkowa dla każdego wdrożenia modułu [A].

Autonomous Module Exception Record (AMER). Formularz wymagany dla aktywacji modułu [A]:

Pole	Opis
AMER ID	Unikalne ID (AMER-YYYY-NNN)
Module	Nazwa modułu [A]
Customer	Organizacja klienta
Jurisdiction	Jurysdykcja operatorów
Legal review	Data i wynik review prawnego (SYLION legal + customer legal)
Risk acknowledgment	Podpis customer security officer
Legal opinion	Niezależna opinia prawna (dla IMEI: N/A — zabronione; dla BTS forcing: recommended)
Scope	Ile operatorów, jakie use cases
Compensating controls	Dodatkowe kontrole (np. monitoring użycia modułu)
SLA exclusion	Potwierdzenie, że moduł wyłączony z SLA
Certification exclusion	Potwierdzenie, że moduł wyłączony z certyfikacji
Review cadence	Częstotliwość przeglądu (annual minimum)
Expiry	Data wygaśnięcia (annual renewal required)
Signatures	Customer: sponsor + security officer + legal; SYLION: sales + legal + CISO

Exclusion from certifiable core claims. Po aktywacji modułu [A]: (a) certyfikacje SYLION (ISO 27001, SOC 2, CC, FedRAMP) nadal obowiązują — ale exclusion modułu [A] ze scope jest documented. (b) Customer nie może powoływać się na certyfikacje SYLION w kontekście modułów [A]. (c) Audit: audytor informowany o modułach [A] aktywnych u klienta i ich explicit exclusion.

Annual review. Co roku: (a) review legalności (czy prawo się nie zmieniło), (b) review skuteczności (czy moduł nadal potrzebny), (c) review ryzyk (czy pojawiły się nowe ryzyka), (d) renewal lub deactivation.

Rozdział 124. Moduły eksperymentalne [E]

124.1 Blind Broker [E]

Status: [E] Eksperymentalny Odbiorca: Architekt | R&D | SOC Wpływ na baseline: Średni Powiązane rozdziały: 124.2, 124.7, 119.6

Blind Broker to rozszerzenie session brokera, w którym broker nie ma dostępu do treści mediów przesyłanych przez sesję — broker „widzi” tylko zaszyfrowane strumienie.

Validated: audio/video (SFrame + WebRTC Insertable Streams). Blind Broker jest zwalidowany dla: (a) Audio: SFrame (RFC 9605) szyfruje audio frames end-to-end. Session broker (WebRTC SFU — Selective Forwarding Unit) routuje encrypted frames bez możliwości ich odszyfrowania. Klucze E2EE negocjowane bezpośrednio między uczestnikami (Messaging Layer Security — MLS). (b) Video: analogicznie — SFrame szyfruje video frames. Broker widzi tylko encrypted payloads, nie treść video. (c) Implementation: WebRTC Insertable Streams API (W3C) umożliwia injection SFrame encryption/decryption w media pipeline przeglądarki.

NOT validated: remote desktop. Blind Broker NIE działa dla remote desktop (Apache Guacamole): (a) Guacamole CVE-2024-35164: Remote Code Execution vulnerability w Guacamole server — broker (Guacamole) procesuje pixel stream w plaintext, więc compromise brokera = access to screen content. (b) Architektura

Guacamole: broker dekoduje RDP/VNC stream i re-koduje do Guacamole protocol — broker MUSI widzieć content. (c) Wniosek: Blind Broker for remote desktop wymaga fundamental redesign (np. pixel-level E2EE z client-side rendering), co jest research problem, nie engineering problem.

RFC 9605 §7.2 known limitations. (a) Metadata leakage: SFrame nie szyfruje frame metadata (size, timing, type) — traffic analysis możliwy. (b) Key management complexity: MLS ratcheting for large groups — scalability issues. (c) Forward secrecy: SFrame ratcheting provides forward secrecy, ale z granularity ratchet period (nie per-frame). (d) Authentication: SFrame authenticates frames, ale not the SFU routing decisions (SFU could drop/reorder frames).

Implementation path. Year 1: prototype (audio-only, 2-party calls). Year 2: group calls (MLS key management). Year 3: video. Year 4+: research into remote desktop Blind Broker (fundamental challenge).

124.2 Micro-watermarking [E]

Status: [E] Eksperymentalny Odbiorca: CISO | SOC | Legal Wpływ na baseline: Niski Powiązane rozdziały: 124.1, 121.9, 121.5

Micro-watermarking to technika steganograficzna umożliwiająca identyfikację źródła wycieku wizualnych treści.

Technika: DCT steganographic fingerprinting. (a) Session broker (lub dedicated watermark module) osadza fingerprint w pixel stream remote desktop. (b) Fingerprint: operator ID + session ID + timestamp, zakodowane w domenie DCT (Discrete Cosine Transform) obrazu. (c) Encoding: low-frequency DCT coefficients modified imperceptibly — invisible to human eye. (d) Robustness: DCT domain survives: JPEG compression, screen photography (camera captures DCT artifacts), resizing, moderate color adjustment. Does not survive: heavy blurring, extreme contrast changes, or small crop of image.

Use case: insider leak tracing. Scenario: document displayed on SYLION remote desktop, operator photographs screen and leaks to media/competitor. Micro-watermark survives photography → forensic analysis of leaked image → extraction of operator ID → identification of leaker. Use in M&A war rooms (121.9), classified-adjacent environments (121.6), board communications (121.9).

Implementation. (a) Watermark injection: in session broker pixel pipeline (after Guacamole rendering, before transmission to client). (b) Watermark extraction: dedicated forensic tool (offline analysis of leaked image). (c) Capacity: ~100 bits embedded per frame (sufficient for: 32-bit operator ID + 32-bit session ID + 32-bit timestamp = 96 bits). (d) Performance impact: minimal (<5ms per frame for DCT embedding).

Privacy implications. (a) Operator informed: operator must be informed that watermarking is active (GDPR Art. 13 — right to be informed about processing). (b) Not covert surveillance: watermarking is security control, not monitoring — used only in forensic investigation. (c) Proportionality: deployed only for high-sensitivity environments (not default). (d) Policy: watermarking policy documented, operator consent where required.

Not a baseline security control. Micro-watermarking jest [E] i nie zastępuje podstawowych kontroli (E2EE, access control, audit). Jest dodatkową warstwą dla specific high-risk scenarios.

124.3 Dark-Matrix variants [E]

Status: [E] Eksperymentalny Odbiorca: Architekt | CISO | R&D Wpływ na baseline: Średni Powiązane rozdziały: 119.6, 124.4, 121.6

Dark-Matrix to wariant wdrożenia Matrix homeservera jako Tor v3 hidden service (.onion), zapewniający najwyższy poziom anonimowości infrastruktury.

Triple encryption. Komunikacja w Dark-Matrix podlega trzem niezależnym warstwom szyfrowania: (a) E2EE: Matrix Megolm/MLS encryption (end-to-end, operator-to-operator). (b) Tor onion routing: trzy warstwy szyfrowania Tor (relay-to-relay). (c) IPsec tunnel: SYLION IPsec IKEv2 (G1→G2→homeserver). Compromise jednej warstwy nie ujawnia treści — wymagane złamanie wszystkich trzech.

No public IP. Dark-Matrix homeserver nie ma publicznego adresu IP: (a) dostępny wyłącznie jako Tor v3 hidden service (.onion address), (b) ISP serwera nie wie, że serwer hostuje komunikator (traffic = Tor relay), (c) subpoena do ISP nie ujawnia lokalizacji serwera (ISP widzi Tor traffic, nie destination). (d) Onion address: 56-character .onion derived from public key (no DNS, no IP leak).

Federation between .onion homeservers. Komunikacja pomiędzy dwoma sovereign SYLION deployments: (a) obie instancje jako .onion hidden services, (b) federation traffic routowany przez sieć Tor, (c) no clearnet exposure (żaden traffic nie opuszcza Tor), (d) latency penalty: 500-1500ms per hop (Tor overhead), ale acceptable for messaging (nie real-time voice).

Implementation with Matrix Synapse. (a) Synapse configured z Tor SOCKS5 proxy, (b) reverse proxy (nginx) listening on Tor hidden service port, (c) federation_domain set to .onion address, (d) TLS certificate: self-signed (Tor provides authentication via .onion key), (e) configuration: federation_verify_certificates: false for .onion (onion key = authentication).

Limitations. (a) Latency: Tor adds 200-500ms per hop → unsuitable for real-time voice/video. (b) Reliability: Tor circuits break periodically → reconnection logic required. (c) Bandwidth: Tor limited bandwidth → not suitable for large file transfers. (d) Dependency on Tor network health: if Tor network attacked/degraded, Dark-Matrix degraded. (e) Metadata: timing correlation attacks possible (advanced state actor monitoring both ends of Tor circuit). (f) Operational complexity: maintaining Tor hidden service requires specialized knowledge.

124.4 Briar / offline fallback [E]

Status: [E] Eksperymentalny Odbiorca: Operator | PM | R&D Wpływ na baseline: Niski Powiązane rozdziały: 121.7, 121.5, 123.4

Briar to protokół P2P mesh messaging, zaprojektowany do działania bez infrastruktury centralnej — komunikacja bezpośrednio pomiędzy urządzeniami.

Protokół Briar. (a) Transport layers: Bluetooth (~10m range), WiFi Direct (~100m range), Tor (when internet available). (b) E2EE: Bramble protocol (similar to Signal Protocol, custom for P2P). (c) No central server: messages stored on devices, propagated through mesh. (d) Delay-tolerant: messages delivered when devices come into contact (store-and-forward).

Use case: internet blackout. Scenariusze, w których Briar jest critical: (a) Civil unrest: rząd wyłącza internet (Białoruś 2020, Myanmar 2021, Iran 2022) — Briar umożliwia lokalną komunikację protest leaders. (b) Natural disaster: infrastruktura telco zniszczona — Briar via Bluetooth/WiFi Direct. (c) Border crossing: operator wyłącza phone/data na granicy — Briar via Bluetooth z towarzyszem podróży. (d) Field operations: remote area bez cellular coverage — local mesh.

Integration z SYLION. (a) Separate profile na GrapheneOS: Briar zainstalowany w izolowanym profilu (GrapheneOS multiple profiles), oddzielony od SYLION main app. (b) No data exchange between profiles: Briar profile nie ma dostępu do SYLION profile (GrapheneOS isolation). (c) Operator uses Briar when SYLION

unavailable (no internet), switches to SYLION when connectivity restored. (d) No automatic sync: messages from Briar are NOT synced to SYLION (different system, different trust model).

2019 Hong Kong reference. Podczas protestów w Hong Kongu 2019: (a) Briar i AirDrop używane do komunikacji, gdy autorytety monitorowały LIHKG forum i Telegram. (b) Mesh propagation umożliwił spread informacji bez centralized server. (c) Lesson: mesh communication critical w scenariuszu state-level censorship.

Limitations. (a) Android only: Briar nie ma iOS client (Apple restrictions on background Bluetooth). (b) Short range: Bluetooth 10m, WiFi Direct 100m — urban environments limit range further. (c) No voice/video: text only (bandwidth insufficient). (d) No file sharing: text messages only (images possible but slow). (e) Contact exchange: requires physical proximity or Tor (bootstrap problem in blackout). (f) Battery: continuous Bluetooth scanning drains battery rapidly.

124.5 Additional media protection experiments [E]

Status: [E] Eksperymentalny Odbiorca: Architekt | R&D Wpływ na baseline: Niski Powiązane rozdziały: 124.1, 124.6

Dodatkowe eksperymenty z ochroną strumieni medialnych wykraczające poza SFrame.

SRTP key validation experiments. (a) Standard SRTP (Secure Real-time Transport Protocol) używa DTLS-SRTP key exchange — klucze negocjowane per media session. (b) Experiment: zewnętrzna walidacja kluczy SRTP (key fingerprint verification via out-of-band channel — podobnie do Signal's safety numbers). (c) Cel: wykrycie MITM na media plane (nawet jeśli SFU compromised, klucze zwalidowane out-of-band). (d) Implementation: key fingerprint displayed to operators, manual verification (call out digits).

Media plane E2EE extensions. (a) Beyond SFrame: experiments z full media plane encryption (nie tylko frame-level, ale transport-level). (b) QUIC-based media transport (replacing RTP): encrypted by default, multiplexed, congestion controlled. (c) MLS for media key management: Message Layer Security protocol for group key management (replacing custom SFrame key distribution). (d) Post-quantum media keys: ML-KEM for media key exchange (future-proofing against quantum decryption of recorded calls).

124.6 Experimental quantum elements [E]

Status: [E] Eksperymentalny Odbiorca: R&D | CISO | Architekt Wpływ na baseline: Niski Powiązane rozdziały: 116.7, 119.3

Elementy kwantowe wykraczające poza standardową kryptografię postkwantową (PQC).

QKD (Quantum Key Distribution). (a) QKD umożliwia wymianę kluczy z gwarancją bezpieczeństwa opartą na fizyce kwantowej (nie na założeniach obliczeniowych). (b) Current limitation: QKD wymaga dedykowanego łącza optycznego (fiber) między nadawcą a odbiorcą → applicable only for datacenter-to-datacenter links. (c) SYLION experiment: QKD key exchange between primary i secondary region (dedicated dark fiber). (d) Timeline: Year 4+ (zależne od dostępności komercyjnych systemów QKD i kosztów dark fiber). (e) Vendors: ID Quantique, Toshiba QKD, QuintessenceLabs.

QRNG (Quantum Random Number Generators). (a) HSM entropy: standard HSMs use hardware RNG (TRNG), ale QRNG offers provably random entropy from quantum processes (photon detection). (b) SYLION experiment: QRNG module jako entropy source dla HSM key generation. (c) Benefit: eliminates concerns about TRNG predictability (theoretical but non-zero). (d) Products: ID Quantique Quantis, QuintessenceLabs qStream. (e) Integration: QRNG → HSM entropy input → key generation. (f) Timeline: Year 2-3 (QRNG modules commercially available, integration straightforward).

Post-quantum experiments beyond NIST. (a) NIST standardized: ML-KEM, ML-DSA, SLH-DSA. (b) Beyond NIST: experiments z alternative PQC schemes: BIKE (code-based KEM, NIST round 4), HQC (code-based KEM, NIST round 4), NTRU (lattice-based, historically significant). (c) Cel: preparedness for scenario where ML-KEM broken (cryptanalytic breakthrough against lattice-based crypto). (d) Hybrid approach: ML-KEM + code-based KEM → resilience against single-algorithm breakthrough.

124.7 Kryteria przejścia z eksperymentalnego do opcjonalnego

Status: [N] Normatywny Odbiorca: PM | CISO | Architekt Wpływ na baseline: Wysoki Powiązane rozdziały: 124.1–124.6, 124.8

Moduł [E] może przejść do statusu [O] (Opcjonalny) po spełnieniu wszystkich poniższych kryteriów.

Production-quality implementation. (a) Code reviewed (peer review + security review), (b) test coverage >80% (unit + integration), (c) performance tested (under production-like load), (d) documentation complete (admin guide, operator guide, API docs), (e) monitoring and alerting implemented, (f) rollback procedure tested.

Security review. (a) Internal security assessment (SYLION security team), (b) penetration test (dedicated scope for the module), (c) threat model (module-specific threats identified and addressed), (d) no known critical or high vulnerabilities at time of transition.

Independent assessment. (a) External expert review (academic or industry expert in relevant domain), (b) for crypto-related modules: independent cryptographic review, (c) assessment report publicly available (or available to customers under NDA).

No known critical issues. (a) All critical bugs fixed, (b) all high bugs fixed or mitigated with documented workaround, (c) medium/low bugs documented in known limitations.

Documented limitations. (a) All known limitations documented, (b) failure modes documented, (c) edge cases documented, (d) contraindications documented (when NOT to use this module).

Opt-in deployment. (a) Module activated only on explicit request (not default), (b) separate configuration (not bundled with core), (c) customer acknowledgment of limitations.

Transition approval. PM proposes transition → CISO reviews security → CTO reviews technical → Risk Committee approves. Transition documented in changelog with effective date.

124.8 Kryteria odrzucenia modułu eksperymentalnego

Status: [N] Normatywny Odbiorca: PM | CISO | R&D Wpływ na baseline: Średni Powiązane rozdziały: 124.7

Moduł [E] jest odrzucany (deprecated/abandoned) gdy spełniony jest co najmniej jeden z poniższych kryteriów.

Fundamental security flaw. Odkryto lukę bezpieczeństwa, która: (a) nie może być naprawiona bez fundamental redesign, (b) wpływa na rdzeń certyfikowalny (naruszenie 123.3), (c) tworzy ryzyko krytyczne dla operatorów. Przykład: gdyby SFrame okazał się fundamentally broken → Blind Broker [E] deprecated.

Legal risk assessment negative. Niezależna ocena prawna stwierdza, że moduł: (a) jest nielegalny w większości target jurysdykcji, (b) tworzy nieakceptowalne ryzyko prawne dla SYLION, (c) jest sprzeczny z wartościami SYLION (np. moduł umożliwiający surveillance). Przykład: IMEI modification nigdy nie przejdzie z [A] do [E] — jest illegal.

Insufficient real-world adoption. Po 18 miesiącach w statusie [E]: (a) <5 customers testing the module, (b) no production use by any customer, (c) feedback overwhelmingly negative. Moduł bez adopcji = koszt utrzymania bez wartości.

Technology superseded. Lepsza alternatywa pojawia się: (a) standardized replacement (np. IETF standard zastępuje custom protocol), (b) superior open-source implementation, (c) hardware evolution makes module obsolete (np. QRNG integrated into standard HSMS → separate QRNG module unnecessary).

Deprecation process. (a) PM proposes deprecation z uzasadnieniem. (b) CISO + CTO review. (c) Customer notification: 6 months advance notice. (d) Graceful shutdown: module deactivated, configuration preserved (for potential future revival). (e) Documentation archived (not deleted — lessons learned preserved).

CZĘŚĆ XVII — ZAŁĄCZNIKI, SZABLONY I MATERIAŁY REFERENCYJNE

Rozdział 125. Szablony OpenAPI, Protobuf i kontraktów

125.1 Management API — OpenAPI skeleton

Status: [R] Rekomendowany Odbiorca: Dev | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 125.2, 125.6, 128.1

Szablon OpenAPI 3.1 dla Management API — zarządzanie operatorami, tenantami, konfiguracją.

openapi: 3.1.0 info: title: SYLION Management API version: 3.0.0 description: | API zarządzania platformą SYLION. Wymaga autentykacji mTLS + FIDO2 token. Dostępne wyłącznie z Zone 5 (management plane). contact: name: SYLION Platform Team email: platform@sylicon.ch license: name: Proprietary servers: - url: https://mgmt.{tenant}.sylicon.internal:8443 description: Tenant management endpoint variables: tenant: default: default description: Tenant identifier security: - mTLS_fido2: [] paths: /api/v3/operators: get: operationId: listOperators summary: Lista operatorów w tenancie tags: [operators] parameters: - name: status in: query schema: type: string enum: [active, suspended, deprovisioned] - name: page in: query schema: type: integer minimum: 1 default: 1 - name: per_page in: query schema: type: integer minimum: 1 maximum: 100 default: 50 responses: '200': description: Lista operatorów content: application/json: schema: \$ref: '#/components/schemas/OperatorList' '401': \$ref: '#/components/responses/Unauthorized' '403': \$ref: '#/components/responses/Forbidden' post: operationId: createOperator summary: Provisioning nowego operatora tags: [operators] requestBody: required: true content: application/json: schema: \$ref: '#/components/schemas/OperatorCreateRequest' responses: '201': description: Operator created content: application/json: schema: \$ref: '#/components/schemas/Operator' '400': \$ref: '#/components/responses/ValidationError' '409': description: Operator already exists /api/v3/operators/{operatorId}: get: operationId: getOperator summary: Szczegóły operatora tags: [operators] parameters: - \$ref: '#/components/parameters/OperatorId' responses: '200': description: Operator details content: application/json: schema: \$ref: '#/components/schemas/Operator' '404': \$ref: '#/components/responses/NotFound' delete: operationId: deprovisionOperator summary: Deprovisioning operatora tags: [operators] parameters: - \$ref: '#/components/parameters/OperatorId' responses: '202': description: Deprovisioning initiated '404': \$ref: '#/components/responses/NotFound' /api/v3/tenants/{tenantId}/config: get: operationId: getTenantConfig summary: Konfiguracja tenanta tags: [tenants] responses: '200': description: Tenant configuration content: application/json: schema: \$ref: '#/components/schemas/TenantConfig' patch: operationId: updateTenantConfig summary: Aktualizacja konfiguracji tenanta tags: [tenants] requestBody: required: true content: application/json: schema: \$ref: '#/components/schemas/TenantConfigPatch' responses: '200': description: Config updated '400': \$ref: '#/components/responses/ValidationError' components: securitySchemes: mTLS_fido2: type: mutualTLS description: mTLS client certificate + FIDO2 assertion parameters: OperatorId: name: operatorId in: path required: true schema: type: string format: uuid schemas: Operator: type: object properties: id: type: string format: uuid display_name: type: string status: type: string enum: [active, suspended, deprovisioned] created_at: type: string format: date-time tier: type: string enum: [STANDARD, PRO, STATE] microvm_region: type: string fido2_registered: type: boolean OperatorList: type: object properties: items: type: array items: \$ref: '#/components/schemas/Operator' total: type: integer page: type: integer OperatorCreateRequest: type: object required: [display_name, tier, region] properties: display_name: type: string minLength: 2 maxLength: 128 tier: type: string enum: [STANDARD, PRO, STATE] region: type: string policy_pack: type: string TenantConfig: type: object properties: tenant_id: type: string format: uuid tier: type: string session_timeout_minutes: type: integer mfa_required: type: boolean pqc_mandatory: type: boolean data_residency_region: type: string custom_policy_pack: type: string TenantConfigPatch: type: object properties: session_timeout_minutes: type: integer minimum: 5 maximum: 1440 custom_policy_pack: type: string responses: Unauthorized: description: Authentication failed content: application/json: schema: \$ref: '#/components/schemas/Error' Forbidden: description: Insufficient permissions content: application/json: schema: \$ref: '#/components/schemas/Error' NotFound: description: Resource not found content: application/json: schema: \$ref: '#/components/schemas/Error' ValidationError: description: Request validation failed content: application/json: schema: \$ref: '#/components/schemas/Error' Error: type: object properties: error_code: type: string message: type: string request_id: type: string format: uuid timestamp: type: string format: date-time

Powyższy szablon definiuje strukturę Management API. Każdy endpoint wymaga autentykacji mTLS + FIDO2. API dostępne wyłącznie z Zone 5. Wszystkie operacje logowane w Zone 4 (audit). Wersjonowanie: /api/v3/ — major version w URL, minor/patch w header (Accept-Version). Rate limiting: 100 req/min per admin user, 1000 req/min per tenant.

125.2 Session API — OpenAPI skeleton

Status: [R] Rekomendowany Odbiorca: Dev | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 125.1, 125.3

openapi: 3.1.0 info: title: SYLION Session API version: 3.0.0 description: | API zarządzania sesjami operatorskimi. Obsługuje session lifecycle: initiation → authentication → establishment → monitoring → termination. paths: /api/v3/sessions: post: operationId: initiateSession summary: Inicjacja sesji operatorskiej tags: [sessions] requestBody: required: true content: application/json: schema: type: object required: [operator_id, target_workload, auth_assertion] properties: operator_id: type: string format: uuid target_workload: type: string enum: [remote_desktop, matrix_messaging, file_access] auth_assertion: type: string description: FIDO2 assertion (base64url) client_certificate_fingerprint: type: string description: SHA-384 of client mTLS cert responses: '201': description: Session initiated content: application/json: schema: \$ref: '#/components/schemas/Session' '401': description: Authentication failed '403': description: Policy denied session /api/v3/sessions/{sessionId}: get: operationId: getSession summary: Status sesji tags: [sessions] responses: '200': description: Session details content: application/json: schema: \$ref: '#/components/schemas/Session' delete: operationId: terminateSession summary: Terminacja sesji tags: [sessions] responses: '200': description: Session terminated /api/v3/sessions/{sessionId}/heartbeat: post: operationId: sessionHeartbeat summary: Heartbeat sesji (keep-alive) tags: [sessions] responses: '200': description: Heartbeat acknowledged '410': description: Session expired components: schemas: Session: type: object properties: id: type: string format: uuid operator_id: type: string format: uuid workload_type: type: string status: type: string enum: [initiating, authenticating, establishing, active, terminating, terminated] microvm_id: type: string g2_endpoint: type: string ipsec_sa_id: type: string created_at: type: string format: date-time expires_at: type: string format: date-time crypto_profile: type: string enum: [hybrid_pqc, pqc_only, legacy_fallback]

Session API obsługuje pełen cykl życia sesji. Heartbeat co 30s (configurable) — brak heartbeat przez 2× interval = session terminated. Crypto profile negocjowany na podstawie tenant policy i operator capabilities.

125.3 Policy API — OpenAPI skeleton

Status: [R] Rekomendowany Odbiorca: Dev | Architekt | Compliance Wpływ na baseline: Średni Powiązane rozdziały: 125.1, 125.4, 113.6

openapi: 3.1.0 info: title: SYLION Policy API version: 3.0.0 description: | API zarządzania politykami bezpieczeństwa (OPA/Rego). Policy packs deployed per-tenant. paths: /api/v3/policies: get: operationId: listPolicies summary: Lista polityk w tenancie tags: [policies] responses: '200': description: Policy list content: application/json: schema: type: object properties: policies: type: array items: \$ref: '#/components/schemas/PolicySummary' post: operationId: createPolicy summary: Wdrożenie nowej polityki tags: [policies] requestBody: required: true content: application/json: schema: \$ref: '#/components/schemas/PolicyCreateRequest' responses: '201': description: Policy created (pending validation) '400': description: Policy syntax error /api/v3/policies/{policyId}/evaluate: post: operationId: evaluatePolicy summary: Dry-run ewaluacji polityki tags: [policies] requestBody: required: true content: application/json: schema: type: object properties: input: type: object description: Test input for policy evaluation responses: '200': description: Evaluation result content: application/json: schema: type: object properties: result: type: boolean decision_reason: type: string matched_rules: type: array items: type: string components: schemas: PolicySummary: type: object properties: id: type: string format: uuid name: type: string type: type: string enum: [access, session, network, data, crypto, compliance] status: type: string enum: [active, draft, deprecated] version: type: string last_updated: type: string format: date-time PolicyCreateRequest: type: object required: [name, type, rego_source] properties: name: type: string type: type: string enum: [access, session, network, data, crypto, compliance] rego_source: type: string description: OPA Rego policy source code description: type: string test_cases: type: array items: type: object properties: input: type: object expected_result: type: boolean

Policy API umożliwia programatyczne zarządzanie politykami. Każda polityka ma dry-run endpoint (evaluate) do testowania przed wdrożeniem. Polityki osłabiające baseline automatycznie odrzucane (125.1 baseline gate w pipeline).

125.4 Audit API — OpenAPI skeleton

Status: [R] Rekomendowany Odbiorca: Dev | Compliance | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 125.1, 116.9, 111.7

openapi: 3.1.0 info: title: SYLION Audit API version: 3.0.0 description: | API dostępu do logów audytowych (Zone 4). Read-only. Write operations are internal-only (audit pipeline). paths: /api/v3/audit/events: get: operationId: queryAuditEvents summary: Zapytanie o eventy audytowe tags: [audit] parameters: - name: start_time in: query required: true schema: type: string format: date-time - name: end_time in: query required: true schema: type: string format: date-time - name: event_type in: query schema: type: string enum: [authentication, authorization, admin_action, config_change, session_lifecycle, security_alert, policy_decision] - name: actor_id in: query schema: type: string format: uuid - name: resource_type in: query schema: type: string - name: outcome in: query schema: type: string enum: [success, failure, denied] responses: '200': description: Audit events content: application/json: schema: type: object properties: events: type: array items: \$ref: '#/components/schemas/AuditEvent' total_count: type: integer continuation_token: type: string /api/v3/audit/export: post: operationId: exportAuditEvents summary: Export audytowy (CSV/JSON) tags: [audit] requestBody: required: true content: application/json: schema: type: object properties: start_time: type: string format: date-time end_time: type: string format: date-time format: type: string enum: [csv, json, json_lines] include_hash_chain: type: boolean default: true responses: '202': description: Export initiated content: application/json: schema: type: object properties: export_id: type: string format: uuid estimated_completion: type: string format: date-time components: schemas: AuditEvent: type: object properties: event_id: type: string format: uuid timestamp: type: string format: date-time event_type: type: string actor: type: object properties: id: type: string format: uuid type: type: string enum: [operator, admin, system, api_client] ip_address_hash: type: string description: SHA-384 hash of source IP resource: type: object properties: type: type: string id: type: string action: type: string outcome: type: string enum: [success, failure, denied] details: type: object hash_chain: type: object properties: previous_hash: type: string current_hash: type: string algorithm: type: string default: SHA-384

Audit API jest read-only — zapis event do audit store odbywa się wewnętrznie (audit pipeline, nie przez API). Hash chain zapewnia integralność: każdy event zawiera hash poprzedniego eventu (append-only verification). Export z hash chain umożliwia offline weryfikację kompletności i integralności logów audytowych.

125.5 Protobuf templates for event schemas

Status: [R] Rekomendowany Odbiorca: Dev | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 125.4, 125.7

```
syntax = "proto3"; package sylion.events.v3; import "google/protobuf/timestamp.proto"; import "google/protobuf/struct.proto"; // Common event envelope
message EventEnvelope { string event_id = 1; // UUID v7 (time-ordered) google.protobuf.Timestamp timestamp = 2; string event_type = 3; // e.g., "session.created",
"auth.failed" string source_zone = 4; // e.g., "zone-4", "zone-5" string source_component = 5; // e.g., "iam-service", "session-broker" string tenant_id = 6; // UUID
Actor actor = 7; Resource resource = 8; string outcome = 9; // "success" | "failure" | "denied" google.protobuf.Struct details = 10; HashChain hash_chain = 11; }
message Actor { string id = 1; // UUID string type = 2; // "operator" | "admin" | "system" string ip_hash = 3; // SHA-384(source_ip) string session_id = 4; // UUID, if
applicable } message Resource { string type = 1; // "operator" | "session" | "policy" | "config" string id = 2; // UUID string zone = 3; // zone where resource resides }
message HashChain { string previous_hash = 1; // SHA-384 of previous event string current_hash = 2; // SHA-384 of this event (excluding this field) string algorithm
= 3; // "SHA-384" } // Specific event types
message SessionCreatedEvent { EventEnvelope envelope = 1; string operator_id = 2; string workload_type = 3; // "remote_desktop" | "matrix" | "file_access" string microvm_id = 4; string g2_endpoint = 5; string crypto_profile = 6; // "hybrid_pqc" | "pqc_only" string ipsec_sa_id = 7; }
message AuthenticationEvent { EventEnvelope envelope = 1; string method = 2; // "fido2" | "mtls" | "fido2+mtls" bool success = 3; string failure_reason = 4; // if
!success int32 attempt_number = 5; string device_fingerprint = 6; // hash of device characteristics } message ConfigChangeEvent { EventEnvelope envelope = 1;
string config_path = 2; // e.g., "tenant.session_timeout" string old_value_hash = 3; // SHA-384 of old value (not plaintext) string new_value_hash = 4; // SHA-384 of
new value string change_ticket = 5; // reference to change request string approval_id = 6; // reference to approval record } message SecurityAlertEvent {
EventEnvelope envelope = 1; string alert_type = 2; // "brute_force" | "anomaly" | "policy_violation" string severity = 3; // "critical" | "high" | "medium" | "low" string
description = 4; repeated string indicators = 5; // IoCs string recommended_action = 6; }
```

Protobuf schemas zapewniają: silne typowanie (compile-time validation), compact serialization (efficient storage), backward compatibility (field numbers), i code generation (Go, Python, Java, TypeScript). Event types rozszerzalne: nowe event types dodawane jako nowe message z EventEnvelope.

125.6 Error model template

Status: [R] Rekomendowany Odbiorca: Dev Wpływ na baseline: Niski Powiązane rozdziały: 125.1–125.4

SYLION Error Model — consistent across all APIs components: schemas: Error: type: object required: [error_code, message, request_id, timestamp] properties: error_code: type: string description: | Machine-readable error code. Format: SYLION-{DOMAIN}-{NUMBER} Domains: AUTH, AUTHZ, SESSION, POLICY, AUDIT,

INFRA, CRYPTO examples: - "SYLION-AUTH-001" # Invalid FIDO2 assertion - "SYLION-AUTHZ-003" # Insufficient role permissions - "SYLION-SESSION-010" # Session expired - "SYLION-POLICY-005" # Policy weakens baseline (rejected) - "SYLION-CRYPTO-002" # Deprecated algorithm requested message: type: string description: Human-readable error description (EN) request_id: type: string format: uuid description: Unique request identifier for correlation timestamp: type: string format: date-time details: type: object description: Additional context (no sensitive data!) properties: field: type: string description: Field that caused the error constraint: type: string description: Constraint that was violated documentation_url: type: string format: uri description: Link to relevant documentation retry_after: type: integer description: Seconds to wait before retry (for rate limiting)

Zasady error handling: (a) error messages NIE zawierają danych wrażliwych (no keys, no tokens, no PII), (b) error codes są stable (nie zmieniają się między wersjami — backward compatible), (c) request_id umożliwia korelację z audit logs, (d) documentation_url prowadzi do troubleshooting guide. Parameterized errors: zamiast „User john@acme.com not found”, zwracamy „User with specified ID not found” (no PII in error).

125.7 Auth token, policy contract, audit record, admin API templates

Status: [R] Rekomendowany Odbiorca: Dev | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 125.1–125.6

Auth token template (JWT-like, but NOT JWT — SYLION uses opaque tokens internally).

```
{ "token_id": "uuid-v7", "issued_at": "2026-04-05T14:28:00Z", "expires_at": "2026-04-05T15:28:00Z", "operator_id": "uuid", "tenant_id": "uuid", "roles": ["operator"], "permissions": ["session:create", "session:read:own"], "auth_methods": ["fido2", "mtls"], "session_binding": "sha384-of-tls-session", "crypto_profile": "hybrid_pqc", "signature": "ml-dsa-87-signature-base64" }
```

Token bound do TLS session (channel binding — zapobiega token theft). Signature: ML-DSA-87 (PQC). Lifetime: max 1h (configurable per tenant policy). Refresh: nie — nowa autentykacja FIDO2 wymagana.

Policy contract template (OPA/Rego).

```
package sylion.policy.session import rego.v1 # Default deny default allow := false # Allow session if all conditions met allow if { input.operator.status == "active" input.operator.fido2_registered == true valid_crypto_profile within_session_limit not geo_blocked } valid_crypto_profile if { input.tenant.pqc_mandatory == true input.requested_profile in ["hybrid_pqc", "pqc_only"] } valid_crypto_profile if { input.tenant.pqc_mandatory == false } within_session_limit if { count(input.operator.active_sessions) < input.tenant.max_concurrent_sessions } geo_blocked if { input.operator.source_country in input.tenant.blocked_countries }
```

Audit record contract (JSON Lines — one record per line, append-only).

```
{ "event_id": "01905a6b-...", "ts": "2026-04-05T14:28:00.000Z", "type": "auth.success", "actor": { "id": "op-uuid", "type": "operator", "ip_hash": "sha384-...", "resource": { "type": "session", "id": "sess-uuid", "outcome": "success", "details": { "method": "fido2", "device": "pixel-8", "chain": { "prev": "sha384-prev", "curr": "sha384-curr" } } } }
```

Admin API template — rozszerza Management API o: /api/v3/admin/tenants (CRUD tenantów — SYLION admin only), /api/v3/admin/certificates (PKI management), /api/v3/admin/hsm (HSM status, key rotation triggers), /api/v3/admin/breakglass (break-glass initiation — dual approval required). Admin API wymaga: SYLION admin role + mTLS + FIDO2 + explicit tenant context.

Rozdział 126. Playbooki bezpieczeństwa i operacji

126.1 YAML playbook format definition

Status: [R] Rekomendowany Odbiorca: SOC | Infra | CISO Wpływ na baseline: Wysoki Powiązane rozdziały: 126.2, 126.3, 129.1

Format YAML dla playbooków SYLION — ustandaryzowany, maszynowo-parsowalny, wersjonowane.

```
# SYLION Playbook Format v3 --- playbook: id: PB-SEC-001 title: "Terminal Loss / Theft Response" version: "3.0.0" classification: INTERNAL owner: SOC Lead last_reviewed: "2026-04-01" next_review: "2026-07-01" trigger: type: event # event | scheduled | manual source: operator_report | mdm_alert | anomaly_detection severity: P2 # P1 | P2 | P3 | P4 sla: response: 30m # max time to start playbook resolution: 4h # target resolution time roles: - role: soc_analyst responsibility: "Initial triage and certificate revocation" - role: platform_engineer responsibility: "MicroVM isolation verification" - role: customer_admin responsibility: "Operator communication" - role: ciso_escalation: true condition: "If data exposure confirmed" preconditions: - "Access to PKI management console" - "Access to MDM platform" - "Customer emergency contact available" steps: - step: 1 action: "Verify report" actor: soc_analyst description: | Confirm terminal loss via: operator report, MDM heartbeat failure (>30min), or anomaly detection (unusual auth pattern). automation: partial # full | partial | manual tool: "SIEM query: device_heartbeat_status" timeout: 10m - step: 2 action: "Revoke device certificate" actor: soc_analyst description: | Immediately revoke mTLS client certificate of lost terminal. This prevents any IPsec session establishment from the device. automation: full tool: "PKI API: POST /certificates/{certId}/revoke" timeout: 5m verification: "Confirm CRL updated and propagated to G1/G2" - step: 3 action: "Terminate active sessions" actor: soc_analyst description: | Force-terminate any active sessions from the lost terminal. automation: full tool: "Session API: DELETE /sessions?device_cert={certFingerprint}" timeout: 5m - step: 4 action: "Remote wipe device" actor: soc_analyst description: | Initiate remote wipe via MDM (GrapheneOS remote wipe). If device offline, wipe queued for next connectivity. automation: full tool: "MDM: remote_wipe command" timeout: 15m - step: 5 action: "Verify MicroVM integrity" actor: platform_engineer description: | Confirm operator's microVM is unaffected (no unauthorized access, no data exfiltration). Review session logs. automation: partial tool: "SIEM + MicroVM management console" timeout: 30m - step: 6 action: "Notify customer admin" actor: soc_analyst description: | Notify customer's designated security contact about terminal loss, actions taken, and next steps (new terminal provisioning). automation: manual tool: "Secure email / phone" timeout: 30m - step: 7 action: "Provision replacement terminal" actor: platform_engineer description: | Ship or provision new terminal kit (Pixel + GL-iNet + FIDO2). Generate new certificates. Operator re-enrollment required. automation: partial tool: "Provisioning system" timeout: 48h escalation: - condition: "Device not wiped within 4h (offline)" action: "Escalate to CISO — potential data exposure" target: ciso - condition: "Unauthorized session detected from lost device" action: "Escalate to P1 — active compromise" target: incident_commander post_incident: - "Document timeline in incident record" - "Update operator status in IAM" - "Review: could this have been prevented?" - "If STATE tier: notify customer per SLA (117.6)" metrics: - "Time to certificate revocation" - "Time to device wipe (if online)" - "Time to customer notification"
```

Format zapewnia: identyfikowalność (PB-ID), wersjonowanie, jasne role, automatyzację (full/partial/manual per step), SLA tracking, i escalation paths. Playbook parsowany automatycznie przez incident management system.

126.2 Markdown playbook format

Status: [R] Rekomendowany Odbiorca: SOC | Infra Wpływ na baseline: Średni Powiązane rozdziały: 126.1, 126.3

Alternatywny format Markdown dla czytelności ludzkiej (YAML format powyżej jest primary, Markdown jako derived format).

```
# PB-SEC-001: Terminal Loss / Theft Response **Severity:** P2 | **SLA Response:** 30 min | **SLA Resolution:** 4h **Owner:** SOC Lead | **Last Review:** 2026-04-01 ## Trigger - Operator reports terminal lost/stolen - MDM heartbeat failure >30 min - Anomaly detection: unusual auth pattern from device ## Steps ### 1. Verify report (SOC Analyst, 10 min) Confirm via: operator report, MDM status, SIEM query. ### 2. Revoke device certificate (SOC Analyst, 5 min) [AUTOMATED] `POST /api/v3/certificates/{certId}/revoke` **Verify:** CRL propagated to all G1/G2 nodes. ### 3. Terminate active sessions (SOC Analyst, 5 min) [AUTOMATED] `DELETE /api/v3/sessions?device_cert={fingerprint}` ### 4. Remote wipe (SOC Analyst, 15 min) [AUTOMATED] MDM remote wipe command. If offline → queued. ### 5. Verify MicroVM integrity (Platform Engineer, 30 min) Check: no unauthorized access, no exfiltration indicators. ### 6. Notify customer (SOC Analyst, 30 min) Secure channel to customer security contact. ### 7. Provision replacement (Platform Engineer, 48h) New terminal kit + new certificates + re-enrollment. ## Escalation - Device not wiped 4h → CISO - Unauthorized session from lost device → P1 ## Post-Incident - Document timeline - Update operator status - Lessons learned review
```

Markdown format generowany automatycznie z YAML (tooling: playbook-to-md converter). Używany do: print-out w SOC (quick reference), onboarding nowych analityków, customer-facing documentation (sanitized version).

126.3 Complete playbook examples

Status: [R] Rekomendowany Odbiorca: SOC | Infra | Legal | CISO Wpływ na baseline: Wysoki Powiązane rozdziały: 126.1, 126.2, 129.1

47.3.1 Playbook: PB-SEC-002 — Workload Compromise Response

playbook: id: PB-SEC-002 title: "Workload (MicroVM) Compromise Response" version: "3.0.0" severity_default: P1 sla: response: 15m resolution: 2h trigger: source: "SIEM alert: microvm_anomaly | IDS signature | operator report" indicators: - "Unusual outbound network traffic from microVM" - "Unexpected process execution in microVM" - "File integrity violation in microVM rootfs" - "Crypto mining indicators" steps: - step: 1 action: "Isolate compromised microVM" actor: soc_analyst description: | Immediately network-isolate the microVM: - Block all egress traffic (firewall rule on host) - Maintain ingress for forensic access only (from Zone 5) - Do NOT terminate the microVM (preserve evidence) automation: full tool: "Firecracker jailer: network isolation command" timeout: 5m critical: true - step: 2 action: "Capture forensic snapshot" actor: platform_engineer description: | Before any remediation: - Snapshot microVM memory (RAM dump) - Snapshot microVM disk (block device copy) - Capture network flow logs (last 24h) - Hash all artifacts (SHA-384) - Store in forensic evidence store (111.8) automation: partial timeout: 30m - step: 3 action: "Assess blast radius" actor: soc_analyst description: | Determine: Is compromise limited to single microVM? - Check: any lateral movement to G2? - Check: any cross-microVM communication? (should be impossible) - Check: HSM/PKI interaction from compromised microVM? - Check: other operators on same physical host? automation: partial timeout: 30m - step: 4 action: "Rotate affected credentials" actor: soc_analyst description: | - Revoke operator's session keys - Rotate operator's PKI certificate - If blast radius includes G2: rotate G2 certificates - If HSM interaction suspicious: initiate HSM audit automation: partial timeout: 30m - step: 5 action: "Provision replacement microVM" actor: platform_engineer description: | - Provision clean microVM from trusted image - New IP address, new certificates - Verify integrity (hash comparison with golden image) - Operator re-authenticates to access new microVM automation: full timeout: 30m - step: 6 action: "Notify affected parties" actor: soc_analyst description: | - Notify operator's organization (customer admin) - If data breach: initiate 117.6 notification procedure - If STATE tier: 15-minute notification SLA automation: manual timeout: 30m - step: 7 action: "Root cause analysis" actor: security_engineer description: | - Analyze forensic artifacts (memory dump, disk, network) - Identify attack vector (vulnerability, misconfiguration, insider) - Determine IoCs (indicators of compromise) - Publish IoCs to detection systems timeout: 72h escalation: - condition: "Lateral movement confirmed (beyond single microVM)" action: "Escalate to CRITICAL — potential platform compromise" target: incident_commander - condition: "HSM interaction from compromised microVM" action: "Escalate to CRITICAL — potential key compromise" target: ciso

47.3.2 Playbook: PB-LEGAL-001 — Legal Seizure Request

playbook: id: PB-LEGAL-001 title: "Legal Seizure / Data Request Response" version: "3.0.0" severity_default: P2 sla: response: 4h resolution: "per legal timeline" trigger: source: "Legal team receives formal data request" types: - "Court order (Swiss jurisdiction)" - "MLAT request (foreign jurisdiction via Swiss FDJP)" - "Emergency disclosure request (imminent threat to life)" - "Regulatory request (DPA investigation)" steps: - step: 1 action: "Validate request authenticity" actor: general_counsel description: | Verify: (a) request from legitimate authority, (b) proper legal instrument (court order, not informal request), (c) correct jurisdiction (Swiss law for Swiss AG data), (d) not a phishing/social engineering attempt. timeout: 4h - step: 2 action: "Assess scope and feasibility" actor: general_counsel description: | Determine: What data is requested? What can SYLION provide? - Communication content: CANNOT provide (E2EE — SYLION does not have decryption keys). Document this clearly. - Metadata: CAN provide (with valid court order): connection logs, authentication events, IP hashes, session timestamps. - Account information: CAN provide: operator ID, tenant, creation date, tier. - Billing: CAN provide: billing records for Swiss AG clients. IMPORTANT: No data from other tenants. Scope strictly limited to identified operator/tenant. timeout: 24h - step: 3 action: "Legal review and challenge (if appropriate)" actor: general_counsel description: | If request is: (a) overbroad — challenge scope, (b) wrong jurisdiction — redirect to correct MLAT channel, (c) targeting journalistic sources — invoke press freedom protections (Swiss Federal Act on Data Protection, Art. 17 journalist privilege), (d) potentially violating operator rights — challenge in court. Swiss law allows: challenge court orders, delay execution pending appeal. Use this right when appropriate. timeout: "varies (days to weeks)" - step: 4 action: "Data collection and production" actor: platform_engineer description: | If legal review confirms compliance required: - Collect only specified data (minimal scope) - Package with chain of custody documentation - Hash all produced data (SHA-384) - Encrypt in transit to requesting authority - Log: what data produced, to whom, on what basis automation: partial timeout: "per court order timeline" - step: 5 action: "Notify affected parties (if permitted)" actor: general_counsel description: | Swiss law generally permits notification of data subject (unlike US NSL/gag orders). Unless court order explicitly prohibits notification: - Notify customer organization - Notify operator (through customer) - Provide: what data was requested, by whom, legal basis If notification prohibited: document prohibition, set calendar reminder to notify when prohibition expires. timeout: "per legal assessment" - step: 6 action: "Document in transparency report" actor: general_counsel description: | Record request in transparency report data: - Jurisdiction - Type of request - Data categories provided - Whether challenged - Whether customer notified Annual publication (117.7) timeout: 5d

Playbooki powyższe stanowią wzorcowe procedury. Każdy deployment STATE powinien mieć customized versions tych playbooków, uwzględniające specyfikę klienta i jurysdykcji.

47.4 126.4–126.6 Failover, onboarding/offboarding, upgrade/rollback playbook structures

Status: [R] Rekomendowany Odbiorca: Infra | SOC | PM Wpływ na baseline: Wysoki Powiązane rozdziały: 126.1–126.3, 110.9, 113.8

126.4 Failover playbook structure (PB-INFRA-001).

Trigger: region health check failure (2× consecutive failed checks, 60s interval). Steps: (1) Confirm region failure (not false positive — check multiple health endpoints), (2) DNS failover initiation (update DNS records to secondary region, TTL-dependent propagation), (3) BGP route advertisement (announce secondary region prefix if anycast), (4) Active session migration (sessions re-establish against secondary G1/G2 — operators experience reconnect), (5) Data consistency verification (check replication lag, identify any data loss within RPO), (6) Customer notification (per 117.6 timelines), (7) Capacity validation (secondary region has sufficient capacity for full load), (8) Monitor secondary region stability, (9) Plan region restoration (when primary recovers). Auto-failover: for individual components (single G1/G2 failure). Manual trigger: for full region evacuation (requires SOC lead approval — prevents split-brain).

126.5 Onboarding/offboarding playbook structure (PB-OPS-001/002).

Onboarding (PB-OPS-001): (1) Customer contract signed → tenant provisioning initiated, (2) Infrastructure provisioning (Terraform — 113.1), (3) Network configuration (VPC, G1/G2 assignment, IPsec profiles), (4) PKI initialization (tenant CA, initial certificates), (5) IAM setup (customer admin account, initial roles), (6) Policy deployment (baseline + customer custom if PRO/STATE), (7) Terminal kit preparation (Pixel imaging, GL-iNet configuration, FIDO2 enrollment), (8) Customer admin training, (9) Operator onboarding (per operator: provisioning, certificate issuance, FIDO2 registration, first login verification), (10) Go-live sign-off.

Offboarding (PB-OPS-002): (1) Contract termination notice received, (2) Data export (customer data export per GDPR portability right), (3) Grace period (30 days — customer can still access data), (4) Data deletion (crypto-shredding: delete tenant KEK → all encrypted data becomes unrecoverable), (5) Certificate revocation (all tenant certificates), (6) Infrastructure deprovisioning, (7) Confirmation to customer (written confirmation that data deleted), (8) Retention exception: audit logs retained per legal obligation (tax: 7 years, security: 2 years).

126.6 Upgrade/rollback playbook structure (PB-INFRA-003).

Upgrade: (1) Change request approved (113.8 for emergency), (2) Staging deployment + testing, (3) Canary deployment (single node, 5% traffic), (4) Monitor canary (30 min minimum, automated health checks), (5) Gradual rollout (10% → 25% → 50% → 100%), (6) Post-deployment verification (smoke tests, integration tests), (7) Customer notification (if user-facing change). Rollback: (1) Rollback trigger (automated: health check failure; manual: SOC decision), (2) Previous version re-deployment (Terraform state rollback), (3) Verification (previous functionality restored), (4) Root cause analysis of failed upgrade, (5) Incident report if customer-impacting. STATE tier: rolling upgrades (zero-downtime) — each node upgraded sequentially with health verification before proceeding to next.

Rozdział 127. Diagramy źródłowe i notacje

127.1 PlantUML — Zone topology

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Infra Wpływ na baseline: Niski Powiązane rozdziały: 127.2, 127.4

```
@startuml
    SYLION_Zone_Topology !theme plain
    skinparam backgroundColor #FEFEFE
    skinparam componentStyle rectangle
    title SYLION 3.0 — Zone Topology

    package "Zone 0 — Endpoints" as Z0 #E8F5E9 {
        [Pixel Terminal\n(GrapheneOS)] as pixel
        [GL-iNet Router\n(WireGuard/IPsec)] as router
        [FIDO2 Key\n(Biometric)] as fido
    }
    package "Zone 1 — Access Gateway" as Z1 #E3F2FD {
        [G1 Gateway\n(IPsec IKEv2 Termination)\n(DDoS Protection)\n(Anycast)] as g1
    }
    package "Zone 2 — Session Gateway" as Z2 #FFF3E0 {
        [G2 Gateway\n(Session Broker)\n(Policy Enforcement)\n(CDR Processing)] as g2
    }
    package "Zone 3 — Operator Workloads" as Z3 #FCE4EC {
        [Firecracker MicroVM\n(Per-Operator)\n(IPsec Endpoint)\n(Remote Desktop)] as microvm1
        [Firecracker MicroVM\n(Per-Operator)] as microvm2
        [Firecracker MicroVM\n(Per-Operator)] as microvm3
    }
    package "Zone 4 — Shared Services" as Z4 #F3E5F5 {
        [SIEM / Logging\n(WORM, Hash Chain)] as siem
        [Monitoring\n(Prometheus/Grafana)] as monitoring
        [Matrix Homeserver\n(Optional, E2EE)] as matrix
        [CDR Engine\n(Multi-engine)] as cdr
    }
    package "Zone 5 — Management Plane" as Z5 #FFF9C4 {
        [IAM Service\n(FIDO2 + mTLS)] as iam
        [PKI / HSM\n(FIPS 140-3)] as hsm
        [Config Management\n(Terraform State)] as config
        [Policy Engine\n(OPA/Rego)] as opa
    }

    pixel --> router : USB-C Ethernet
    router --> g1 : IPsec IKEv2\n(PQC Hybrid)
    fido --> pixel : FIDO2 BLE/NFC
    g1 --> g2 : mTLS + IPsec
    g2 --> microvm1 : IPsec SA\n(Per-Operator)
    g2 --> microvm2 : IPsec SA
    g2 --> microvm3 : IPsec SA
    g2 --> cdr : File sanitization
    g2 --> matrix : E2EE messaging
    microvm1 --[hidden]-> microvm2
    microvm2 --[hidden]-> microvm3
    Z3 --> siem : Security telemetry
    Z2 --> siem : Session logs
    Z1 --> siem : Access logs
    Z5 --> Z1 : Management
    Z5 --> Z2 : Management
    Z5 --> Z3 : Provisioning
    Z5 --> Z4 : Configuration

    note right of Z0 No data persisted on endpoints. Thin Client model.
    note right of Z3 MicroVMs isolated: no cross-VM communication.
    Boot <150ms.
    end note
    @enduml
```

Diagram zone topology pokazuje 6 stref bezpieczeństwa SYLION z kluczowymi komponentami i przepływami komunikacji. Strzałki wskazują kierunek inicjacji połączenia, nie kierunek danych (dane flowing bidirectionally w ramach ustanowionych tuneli IPsec).

127.2 PlantUML — Operator access flow

Status: [R] Rekomendowany Odbiorca: Architekt | SOC Wpływ na baseline: Średni Powiązane rozdziały: 127.1, 127.3

```
@startuml
    SYLION_Operator_Access_Flow !theme plain
    skinparam sequenceMessageAlign center
    title SYLION 3.0 — Operator Session Establishment actor

    participant "Operator" as op
    participant "Pixel Terminal\n(GrapheneOS)" as pixel
    participant "GL-iNet Router" as router
    participant "G1 Gateway" as g1
    participant "IAM Service\n(Zone 5)" as iam
    participant "G2 Session Broker\n(Zone 2)" as g2
    participant "Policy Engine\n(OPA)" as opa
    participant "Firecracker MicroVM\n(Zone 3)" as vm

    op --> pixel : FIDO2 biometric auth
    pixel --> pixel : Verify FIDO2 assertion\n(local + Titan M2)
    pixel --> router : USB-C Ethernet\n(wired connection)
    router --> g1 : IKEv2 SA negotiation\n(ML-KEM-1024 + X25519\nML-DSA-87 + Ed25519)
    g1 --> iam : Verify client certificate\n(mTLS)
    iam --> iam : Check certificate status\n(CRL/OCSP)
    iam --> g1 : Auth token issued
    g1 --> g2 : Forward auth token\n+ session request
    g2 --> opa : Evaluate session policy
    opa --> opa : Check: operator active?\nFIDO2 registered?\nCrypto profile valid?\nGeo-block? Session limit?
    opa --> g2 : Decision: ALLOW
    g2 --> vm : Establish IPsec SA\n(operator-specific)
    vm --> g2 : SA established
    g2 --> g1 : Session parameters\n(microVM endpoint,\ncrypto profile)
    g1 --> router : IPsec tunnel parameters
    router --> pixel : Tunnel active
    pixel --> vm : Remote Desktop\n(RDP over IPsec,\nend-to-end encrypted)
    note over g1, g2 G1 terminates outer IPsec. G2 establishes inner IPsec to microVM. Double IPsec = defense in depth.
    end note
    note over vm MicroVM boot on-demand or pre-provisioned. Boot time <150ms.
    end note
    @enduml
```

127.3 PlantUML — File CDR pipeline

Status: [R] Rekomendowany Odbiorca: Architekt | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 127.1, 127.2

@startuml SYLION_CDR_Pipeline !theme plain title SYLION 3.0 — Content Disarm & Reconstruction (CDR) Pipeline start :Operator uploads file\nvia remote desktop; :File intercepted by\nG2 CDR proxy; :File queued in\nstaging area\n(encrypted, ephemeral); if (File size > max?) then (yes) :REJECT\n(log: oversized); stop else (no) endif :File type identification\n(magic bytes + extension); if (File type allowed?) then (yes) else (no) :REJECT\n(log: blocked type); stop endif fork :CDR Engine 1\n(structural analysis); fork again :CDR Engine 2\n(threat scanning); fork again :CDR Engine 3\n(macro/script removal); end fork if (Any engine flags threat?) then (yes) :QUARANTINE\n(log: threat detected); :Alert SOC; stop else (no) endif :Reconstruct clean file\n(strip metadata,\nrebuild structure,\nremove active content); :Hash verification\n(SHA-384 of output); :Clean file delivered\nto operator microVM; :Audit log entry\n(file hash, engines used,\ndecision, timestamp); stop @enduml

Pipeline CDR zapewnia, że żaden plik nie dociera do microVM operatora bez sanitizacji. Multi-engine approach (fork) zapewnia, że single-engine bypass nie omija detekcji. Rekonstrukcja (nie samo skanowanie) eliminuje zero-day exploits ukryte w structural elements pliku.

127.4 Mermaid — Session establishment sequence

Status: [R] Rekomendowany Odbiorca: Dev | Architekt Wpływ na baseline: Średni Powiązane rozdziały: 127.1, 127.2

sequenceDiagram participant Op as Operator (Pixel) participant R as GL-iNet Router participant G1 as G1 Gateway participant IAM as IAM Service participant G2 as G2 Broker participant OPA as Policy Engine participant VM as Firecracker MicroVM Op->>R: FIDO2 authenticated, request session R->>G1: IKEv2 INIT (ML-KEM + X25519) G1->>G1: Verify client cert (mTLS) G1->>IAM: Authenticate (cert + FIDO2 assertion) IAM->>IAM: Validate credentials IAM->>G1: Auth token G1->>G2: Session request + token G2->>OPA: Evaluate policy OPA-->>G2: ALLOW G2->>VM: Provision/wake microVM VM-->>G2: Ready (IPsec SA params) G2-->>G1: Session established G1-->>R: Tunnel parameters R-->>Op: Connected Op->>VM: Remote Desktop (E2E encrypted)

127.5 Mermaid — Incident response sequence

Status: [R] Rekomendowany Odbiorca: SOC | CISO Wpływ na baseline: Średni Powiązane rozdziały: 126.3, 127.4

sequenceDiagram participant SIEM as SIEM (Zone 4) participant SOC as SOC Analyst participant PE as Platform Engineer participant CISO as CISO participant CA as Customer Admin SIEM->>SOC: Alert: MicroVM anomaly detected SOC->>SOC: Triage (5 min) SOC->>PE: Request: isolate microVM PE->>PE: Network isolation (Firecracker jailer) PE-->>SOC: Isolated, forensic access only SOC->>PE: Request: forensic snapshot PE->>PE: RAM dump + disk snapshot + network logs PE-->>SOC: Artifacts stored (SHA-384 hashed) SOC->>SOC: Assess blast radius alt Blast radius > single microVM SOC->>CISO: Escalate to CRITICAL CISO->>CISO: Activate incident commander end SOC->>SOC: Rotate affected credentials PE->>PE: Provision clean replacement microVM SOC->>CA: Notify customer (per SLA timeline) CA-->>SOC: Acknowledged SOC->>SOC: Root cause analysis (72h) SOC->>SIEM: Publish IoCs

48.6 127.6–127.8 ArchiMate, C4, logical, network, flow, RACI guidance

Status: [R] Rekomendowany Odbiorca: Architekt | PM Wpływ na baseline: Niski Powiązane rozdziały: 127.1–127.5

127.6 ArchiMate notation guidance. SYLION architecture documented in ArchiMate 3.2: (a) Business Layer: services offered (STANDARD, PRO, STATE), processes (onboarding, incident response, compliance), roles (operator, admin, SOC). (b) Application Layer: components (G1, G2, Session Broker, IAM, PKI, CDR), interfaces (APIs — 125.1-125.4), data objects (operator data, audit logs, policies). (c) Technology Layer: infrastructure (Firecracker, Kubernetes, HSM, VPS), networks (zones, IPsec tunnels), deployment nodes (regions). ArchiMate diagrams to be maintained in Archi tool (open-source).

127.7 C4 model — context and container. C4 Context diagram: SYLION System ← interacts with → Operators, Customer Admins, Cloud Providers, HSM Vendors, Certificate Authorities, SIEM/SOC tools. C4 Container diagram: within SYLION system boundary: G1 Container (IPsec termination), G2 Container (session brokering), MicroVM Fleet (operator workloads), IAM Service, PKI Service, Policy Engine, Audit Pipeline, Matrix Homeserver (optional), CDR Engine, Monitoring Stack. Each container: technology stack, responsibilities, interfaces. C4 diagrams maintained as PlantUML (C4-PlantUML library).

127.8 RACI diagram format. Responsibility Assignment Matrix for SYLION key processes:

Process	SYLION CTO	SYLION CISO	SOC	Infra	Customer Admin	Operator
Operator provisioning	I	I	I	R	A	C
Incident response (platform)	I	A	R	C	I	I
Certificate rotation	I	A	I	R	I	—
Policy change	C	A	I	R	C	—
DR exercise	I	A	R	R	C	—
Security patch	I	A	I	R	I	—
Break-glass activation	—	A	R	R	I	—

R = Responsible (wykonuje), A = Accountable (decyduje), C = Consulted, I = Informed.

Rozdział 128. Przykładowe skrypty CI/CD i IaC

128.1 GitHub Actions pipeline template

Status: [R] Rekomendowany Odbiorca: Dev | Infra Wpływ na baseline: Wysoki Powiązane rozdziały: 113.1, 128.2, 128.4

.github/workflows/sylian-deploy.yml name: SYLION Build → Test → Security → Sign → Deploy on: push: branches: [main] pull_request: branches: [main] permissions: contents: read id-token: write # For OIDC to Vault env: REGISTRY: ghcr.io/sylian IMAGE_PREFIX: sylian jobs: build: runs-on: ubuntu-latest outputs: image_tag: \${{ steps.meta.outputs.tags }} steps: - uses: actions/checkout@v4 - name: Build container image run: | docker build \ --build-arg BUILD_DATE=\$(date -u


```
+%Y-%m-%dT%H:%M:%SZ" \ --build-arg GIT_SHA=${{ github.sha }} \ -t ${{ env.REGISTRY }}/${{ env.IMAGE_PREFIX }}-${{ matrix.component }}:${{ github.sha }} \ -f
components/${{ matrix.component }}/Dockerfile . strategy: matrix: component: [g1-gateway, g2-broker, iam-service, policy-engine, audit-pipeline] test: needs: build
runs-on: ubuntu-latest steps: - uses: actions/checkout@v4 - name: Unit tests run: make test-unit COMPONENT=${{ matrix.component }} - name: Integration tests
run: make test-integration COMPONENT=${{ matrix.component }} - name: Policy tests (OPA) if: matrix.component == 'policy-engine' run: | opa test policies/ -v --
coverage --threshold 90 strategy: matrix: component: [g1-gateway, g2-broker, iam-service, policy-engine, audit-pipeline] security-scan: needs: build runs-on:
ubuntu-latest steps: - name: Container image scan (Trivy) uses: aquasecurity/trivy-action@master with: image-ref: ${{ env.REGISTRY }}/${{ env.IMAGE_PREFIX }}-${{
matrix.component }}:${{ github.sha }} severity: CRITICAL,HIGH exit-code: 1 # Fail on critical/high - name: SAST scan (Semgrep) uses: returntocorp/semgrep-
action@v1 with: config: p/owasp-top-ten p/security-audit - name: Dependency audit run: | # Check for known vulnerable dependencies make audit-deps
COMPONENT=${{ matrix.component }} - name: Secrets scan (Gitleaks) uses: gitleaks/gitleaks-action@v2 strategy: matrix: component: [g1-gateway, g2-broker, iam-
service, policy-engine, audit-pipeline] sign: needs: [test, security-scan] if: github.ref == 'refs/heads/main' runs-on: ubuntu-latest steps: - name: Sign container image
(Cosign + ML-DSA-87) run: | # Cosign with PQC signature (custom signing key from Vault) vault-login # OIDC auth to HashiCorp Vault cosign sign \ --key
hashivault://syliion/signing-key \ --annotations "build.sha=${{ github.sha }}" \ --annotations "build.date=$(date -u +%Y-%m-%dT%H:%M:%SZ)" \ ${{ env.REGISTRY
}}/${{ env.IMAGE_PREFIX }}-${{ matrix.component }}:${{ github.sha }} - name: Generate SBOM run: | syft ${{ env.REGISTRY }}/${{ env.IMAGE_PREFIX }}-${{
matrix.component }}:${{ github.sha }} \ -o spdx-json > sbom-${{ matrix.component }}.json - name: Attest SBOM run: | cosign attest \ --key
hashivault://syliion/signing-key \ --predicate sbom-${{ matrix.component }}.json \ --type spdxjson \ ${{ env.REGISTRY }}/${{ env.IMAGE_PREFIX }}-${{
matrix.component }}:${{ github.sha }} strategy: matrix: component: [g1-gateway, g2-broker, iam-service, policy-engine, audit-pipeline] deploy-staging: needs: sign if:
github.ref == 'refs/heads/main' environment: staging runs-on: ubuntu-latest steps: - name: Deploy to staging run: | # ArgoCD sync for staging argocd app set
syliion-staging \ --parameter image.tag=${{ github.sha }} argocd app sync syliion-staging --prune - name: Smoke tests run: make test-smoke ENV=staging - name:
Security integration tests run: make test-security ENV=staging deploy-production: needs: deploy-staging if: github.ref == 'refs/heads/main' environment:
production runs-on: ubuntu-latest steps: - name: Canary deployment (5%) run: | argocd app set syliion-prod \ --parameter canary.weight=5 \ --parameter
canary.image.tag=${{ github.sha }} argocd app sync syliion-prod - name: Monitor canary (30 min) run: | # Automated health check monitoring make monitor-canary
DURATION=30m THRESHOLD=0.1 - name: Full rollout run: | argocd app set syliion-prod \ --parameter image.tag=${{ github.sha }} argocd app sync syliion-prod --
prune
```

Pipeline wymusza: build → unit/integration test → security scan (container, SAST, dependency, secrets) → sign (PQC signature + SBOM attestation) → staging
 deploy + smoke test → canary production → full rollout. Failure at any stage blocks deployment.

49.2 128.2–128.7 IaC, Ansible, OPA, Kubernetes, Prometheus, backup templates

Status: [R] Rekomendowany Odbiorca: Infra | Dev | SOC Wpływ na baseline: Wysoki Powiązane rozdziały: 128.1, 113.1–113.9

128.2 Terraform module template — operator environment.

```
# modules/operator-environment/main.tf module "operator_microvm" { source = "../firecracker-microvm" operator_id = var.operator_id tenant_id = var.tenant_id
tier = var.tier # STANDARD | PRO | STATE region = var.region vcpu_count = var.tier == "STATE" ? 4 : 2 memory_mb = var.tier == "STATE" ? 8192 : 4096 rootfs_image
= var.golden_image_id enable_sev_snp = var.tier == "STATE" encryption_key_id = vault_transit_key.operator_dek.id network_config = { vpc_id = var.tenant_vpc_id
subnet_id = var.workload_subnet_id sg_ids = [module.operator_sg.id] } tags = { tenant = var.tenant_id operator = var.operator_id tier = var.tier managed =
"terraform" } } resource "vault_transit_key" "operator_dek" { backend = "transit" name = "operator-${var.operator_id}-dek" type = "aes256-gcm96" }
```

128.3 Ansible role template — G1/G2 hardening.

```
# roles/gateway-hardening/tasks/main.yml --- - name: Disable unnecessary services ansible.builtin.systemd: name: "{{ item }}" state: stopped enabled: false loop: -
avahi-daemon - cups - bluetooth ignore_errors: true - name: Configure sysctl security parameters ansible.posix.sysctl: name: "{{ item.key }}" value: "{{ item.value }}"
sysctl_set: true loop: - { key: "net.ipv4.ip_forward", value: "1" } - { key: "net.ipv4.conf.all.rp_filter", value: "1" } - { key: "net.ipv4.conf.all.accept_redirects", value: "0" } - {
key: "net.ipv6.conf.all.accept_redirects", value: "0" } - { key: "kernel.randomize_va_space", value: "2" } - { key: "kernel.kptr_restrict", value: "2" } - name: Configure
strongSwan IPsec (PQC hybrid) ansible.builtin.template: src: ipsec.conf.j2 dest: /etc/strongswan/swanctl/swanctl.conf owner: root group: root mode: '0600' notify:
restart strongswan - name: Deploy firewall rules (nftables) ansible.builtin.template: src: nftables.conf.j2 dest: /etc/nftables.conf mode: '0600' notify: reload nftables
```

128.4 OPA/Rego policy test template.

```
# policies/session_policy_test.rego package syliion.policy.session_test import rego.v1 import data.syliion.policy.session_test allow_valid_operator if { session.allow
with input as { "operator": { "status": "active", "fido2_registered": true, "active_sessions": [], "tenant": { "pqc_mandatory": true, "max_concurrent_sessions": 5,
"blocked_countries": ["CN", "RU"] }, "requested_profile": "hybrid_pqc", "operator": { "source_country": "PL", "status": "active", "fido2_registered": true, "active_sessions":
[] } } } test_deny_suspended_operator if { not session.allow with input as { "operator": { "status": "suspended", "fido2_registered": true, "active_sessions": [], "tenant":
{ "pqc_mandatory": false, "max_concurrent_sessions": 5, "blocked_countries": [], "requested_profile": "hybrid_pqc" } } } test_deny_geo_blocked if { not session.allow
with input as { "operator": { "status": "active", "fido2_registered": true, "active_sessions": [], "source_country": "CN", "tenant": { "pqc_mandatory": false,
"max_concurrent_sessions": 5, "blocked_countries": ["CN", "RU"] }, "requested_profile": "hybrid_pqc" } }
```

128.5 Session broker Kubernetes manifest.

```
apiVersion: apps/v1 kind: Deployment metadata: name: g2-session-broker namespace: syliion-platform spec: replicas: 3 selector: matchLabels: app: g2-session-
broker template: metadata: labels: app: g2-session-broker spec: serviceAccountName: g2-broker-sa containers: - name: broker image: ghcr.io/syliion/syliion-g2-
broker:v3.0.0 ports: - containerPort: 8443 name: https env: - name: VAULT_ADDR value: "https://vault.syliion.internal:8200" - name: OPA_ADDR value: "http://policy-
engine.syliion-platform:8181" resources: requests: cpu: "500m" memory: "1Gi" limits: cpu: "2" memory: "4Gi" livenessProbe: httpGet: path: /healthz port: 8443
scheme: HTTPS initialDelaySeconds: 10 periodSeconds: 15 readinessProbe: httpGet: path: /readyz port: 8443 scheme: HTTPS initialDelaySeconds: 5 periodSeconds:
10
```

128.6 Prometheus alerting rules template.

```
groups: - name: syliion-platform-alerts rules: - alert: HighAuthFailureRate expr: rate(syliion_auth_failures_total[5m]) > 10 for: 2m labels: severity: warning team: soc
annotations: summary: "High authentication failure rate" description: "Auth failures: {{ $value }}/s (threshold: 10/s)" - alert: MicroVMBootTimeout expr:
syliion_microvm_boot_duration_seconds > 5 for: 1m labels: severity: critical team: infra annotations: summary: "MicroVM boot exceeds 5s (target: <150ms)" - alert:
CertificateExpiringSoon expr: syliion_certificate_expiry_days < 30 labels: severity: warning team: infra annotations: summary: "Certificate {{ $labels.cert_name }}
```


expires in {{ \$value }} days" - alert: SLAAvailabilityAtRisk expr: 1 - (rate(sylian_request_errors_total[1h]) / rate(sylian_requests_total[1h])) < 0.999 for: 10m labels: severity: critical team: soc annotations: summary: "Availability below 99.9% — PRO SLA at risk"

128.7 Backup job template.

apiVersion: batch/v1 kind: CronJob metadata: name: sylian-backup-daily namespace: sylian-platform spec: schedule: "0 2 * * *" # 02:00 UTC daily jobTemplate: spec: template: spec: containers: - name: backup image: ghcr.io/sylian/sylian-backup:v3.0.0 env: - name: BACKUP_TARGETS value: "iam-db,audit-db,config-store,pki-state" - name: BACKUP_ENCRYPTION_KEY valueFrom: secretKeyRef: name: backup-encryption-key key: kek - name: BACKUP_DESTINATION value: "s3://sylian-backups-\${REGION}/" - name: CROSS_REGION_COPY value: "true" - name: RETENTION_DAYS value: "90" - name: IMMUTABLE value: "true" # S3 Object Lock command: - /usr/local/bin/sylian-backup - --verify-after-write - --hash-algorithm=sha384 - --notify-on-failure=soc@sylian.ch restartPolicy: OnFailure

Szablony CI/CD i IaC powyższe stanowią punkt wyjścia (starter templates). Każdy deployment customizuje je do swoich potrzeb. Wszystkie szablony: (a) wersjonowane w Git, (b) reviewed (PR process), (c) tested (CI pipeline), (d) signed (ML-DSA-87).

Rozdział 129. Checklisty audytowe i formularze

129.1 Production readiness checklist

Status: [N] Normatywny Odbiorca: Infra | SOC | CISO | PM Wpływ na baseline: Krytyczny Powiązane rozdziały: 119.8, 129.2, 129.3

Pełna checklist, którą musi spełniać każdy deployment SYLION przed oznaczeniem jako produkcyjny.

Infrastructure (15 items).

- ☐ 1. Compute provisioned per tier requirements (109.1–109.5)
- ☐ 2. Network segmentation verified (zones 0-5 isolated, pentest confirmed)
- ☐ 3. G1 gateway deployed (HA pair minimum), health checks active
- ☐ 4. G2 session broker deployed (HA), load balanced
- ☐ 5. Firecracker microVM hosts provisioned, jailer configured
- ☐ 6. Storage provisioned (hot/warm/cold tiers, encryption at rest verified)
- ☐ 7. Backup infrastructure operational (3-2-1 rule, cross-region copy tested)
- ☐ 8. DNS configured (internal + external, DNSSEC enabled)
- ☐ 9. Monitoring stack operational (Prometheus + Grafana + alerting)
- ☐ 10. Logging pipeline operational (Zone 4 SIEM ingestion verified)
- ☐ 11. CDR engine deployed and tested (multi-engine, file type coverage verified)
- ☐ 12. Load balancer configured (TLS termination at G1 only)
- ☐ 13. DDoS protection active (anycast or cloud-based)
- ☐ 14. Capacity headroom verified (>30% free capacity for burst)
- ☐ 15. DR site provisioned and tested (at least one failover test completed)

Security (20 items).

- ☐ 16. IPsec IKEv2 with PQC hybrid profiles configured and tested
- ☐ 17. HSM operational (FIPS 140-3 for STATE, FIPS 140-2 minimum for others)
- ☐ 18. PKI initialized (root CA, intermediate CAs, per-tenant sub-CAs)
- ☐ 19. FIDO2 authentication tested (registration + authentication flow)
- ☐ 20. mTLS configured for all internal communication
- ☐ 21. No deprecated crypto algorithms in use (scan verified)
- ☐ 22. Certificate rotation procedure tested
- ☐ 23. Key rotation procedure tested (HSM key rotation)
- ☐ 24. Firewall rules reviewed and minimal (deny-all default)
- ☐ 25. Vulnerability scan completed (no critical/high unpatched)
- ☐ 26. Penetration test completed (no critical findings unresolved)
- ☐ 27. SIEM correlation rules active (brute force, anomaly, privilege escalation)
- ☐ 28. Break-glass procedure tested (activation + audit + revocation)
- ☐ 29. Incident response playbooks reviewed and assigned
- ☐ 30. Security monitoring 24/7 (on-call rotation confirmed)
- ☐ 31. OS hardening applied (CIS benchmarks or equivalent)
- ☐ 32. Container images scanned (no critical CVEs)
- ☐ 33. SBOM generated for all deployed components

- ☐ 34. Code signing verified (all deployed artifacts signed)
- ☐ 35. Secrets management operational (Vault, no secrets in code/config)

Operational (15 items).

- ☐ 36. IAM service operational (user provisioning tested)
- ☐ 37. Policy engine operational (baseline policies deployed)
- ☐ 38. Audit pipeline operational (events flowing to SIEM)
- ☐ 39. Operator onboarding procedure tested (end-to-end)
- ☐ 40. Operator offboarding procedure tested
- ☐ 41. Runbooks documented for all operational scenarios
- ☐ 42. On-call rotation established (SOC + Infra)
- ☐ 43. Escalation path documented and tested
- ☐ 44. Change management process operational
- ☐ 45. Capacity monitoring and alerting active
- ☐ 46. Performance baselines established
- ☐ 47. SLA monitoring dashboard operational
- ☐ 48. Customer communication channels established
- ☐ 49. Documentation complete (admin guide, operator guide)
- ☐ 50. Training completed (SOC team, Infra team, support team)

Compliance (5 items).

- ☐ 51. Data Processing Agreement signed with all customers
- ☐ 52. Sub-processor list published
- ☐ 53. Privacy policy published
- ☐ 54. Records of processing activities documented
- ☐ 55. DPIA completed (if applicable)

Sign-off. CTO: ____ | CISO: ____ | COO: ____ | Date: ____

50.2 129.2–129.8 Security, compliance, partner, incident, risk exception, change request, deployment acceptance forms

Status: [R] Rekomendowany Odbiorca: SOC | Compliance | Infra | Legal | PM Wpływ na baseline: Wysoki Powiązane rozdziały: 129.1, 118.7, 117.8

129.2 Security readiness checklist (30+ items). Fokus na security-specific readiness: crypto configuration verified, HSM health, PKI chain of trust, FIDO2 enrollment rates, vulnerability posture (no critical CVEs), pentest findings closure rate, SIEM rule coverage, incident response readiness, break-glass tested, secrets audit (no leaked secrets), network segmentation pentest, container security posture, supply chain verification (SBOM review), security training completion, security metrics baseline. Audytor: CISO sign-off required.

129.3 Compliance readiness checklist (20+ items). Pre-audit preparation: GDPR records of processing complete, DPIAs completed, data subject request process tested, privacy policy current, sub-processor agreements current, data retention implementation verified, cross-border transfer mechanisms in place, ISO 27001 SoA current, SOC 2 control evidence collected, regulatory notifications current (NIS2 registration if applicable), third-party assessments current, employee training records complete. Audytor: General Counsel + Compliance Officer sign-off.

129.4 Partner deployment checklist. Dla partnerów wdrożeniowych (resellers, system integrators): partner certification verified, partner NDA signed, partner security assessment passed, partner staff trained on SYLION, deployment playbook reviewed, customer hand-off process agreed, support escalation path defined, branding/white-label scope agreed (if applicable), SLA allocation between partner and SYLION defined.

129.5 Incident report form template.

Pole	Wartość
Incident ID	INC-YYYY-NNN
Date/Time detected	
Date/Time resolved	
Severity	P1/P2/P3/P4
Affected tier(s)	STANDARD/PRO/STATE
Affected tenant(s)	
Affected operators (count)	
Description	
Root cause	

Timeline of events	
Actions taken	
Data exposed (if any)	
GDPR breach?	Yes/No
NIS2 reportable?	Yes/No
Customer notification sent?	Yes/No, date/time
Prevention measures	
Lessons learned	
Author	
Reviewed by	
Approved by	CISO

129.6 Risk exception form template. (per 118.7): Exception ID, risk ID reference, exception scope, business justification, risk analysis (inherent risk, compensating controls, residual risk), requested duration, requestor, reviewer (compliance), approver (per 118.3 thresholds), expiry date, renewal process.

129.7 Change request form template. (per 117.8): Change ID, title, description, type (standard/normal/emergency), affected components, affected tenants, risk assessment (impact × likelihood), rollback plan, testing performed, approvals (engineer + reviewer + for emergency: security lead), scheduled window, post-change verification steps.

129.8 Deployment acceptance form template. Customer sign-off na zakończenie wdrożenia: deployment scope confirmed, functionality tested (operator login, remote desktop, messaging), security configuration verified, SLA parameters confirmed, training delivered, documentation provided, support channels established, go-live date confirmed. Signatures: Customer Project Sponsor, Customer Security Officer, SYLION Deployment Lead, SYLION CISO.

Rozdział 130. Matryce uprawnień i ról

130.1 RBAC master matrix

Status: [N] Normatywny Odbiorca: Architekt | CISO | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 130.2, 130.4, 120.1

Pełna macierz RBAC: role × zasoby × dozwolone operacje.

Zasób / Operacja	SYLION SuperAdmin	SYLION Admin	SOC Analyst	Tenant Admin (Customer)	Operator	Auditor (Read-Only)
Tenant management						
Create tenant	CRUD	—	—	—	—	R
Modify tenant config	CRUD	RU	R	RU (own)	—	R
Delete tenant	D	—	—	—	—	—
Operator management						
List operators	R	R	R	R (own tenant)	—	R
Create operator	CRU	CRU	—	C (own tenant)	—	—
Suspend operator	U	U	U (emergency)	U (own tenant)	—	—
Delete operator	D	D	—	D (own tenant)	—	—
Session management						
View sessions	R	R	R	R (own tenant)	R (own)	R
Create session	—	—	—	—	C	—
Terminate session	D	D	D (emergency)	D (own tenant)	D (own)	—
Certificates/PKI						
Issue certificate	C	C	—	—	—	—
Revoke certificate	D	D	D (emergency)	—	—	—
Rotate CA	CU	—	—	—	—	—
HSM operations						
View HSM status	R	R	R	—	—	R
Key generation	C	C	—	—	—	—
Key rotation	U	U	—	—	—	—
Key destruction	D	—	—	—	—	—
Audit logs						
View own tenant logs	R	R	R	R (own)	—	R
Export audit logs	R	R	R	R (own)	—	R
Delete audit logs	—	—	—	—	—	—

Policy management						
View policies	R	R	R	R (own)	—	R
Create/modify policy	CRU	CRU	—	CRU (own, restricted)	—	—
Delete policy	D	D	—	D (own custom)	—	—
Infrastructure						
View infrastructure	R	R	R	—	—	R
Modify infrastructure	CRUD	CRU	—	—	—	—
Break-glass access	✓	✓ (with dual approval)	✓ (with escalation)	—	—	—

Legenda: C = Create, R = Read, U = Update, D = Delete. „own” = w ramach własnego tenanta. „emergency” = tylko w sytuacji awaryjnej z audit trail. SuperAdmin: restricted to ≤3 individuals, dual-approval for destructive operations.

51.2 130.2–130.7 ABAC, admin privileges, tenant delegation, incident response, separation of duties, break-glass matrices

Status: [N] Normatywny Odbiorca: CISO | Architekt | Compliance Wpływ na baseline: Krytyczny Powiązane rozdziały: 130.1, 120.1, 118.7

130.2 ABAC attributes matrix.

Atrybut	Typ	Źródło	Użycie w decyzjach polityk
operator.status	Enum	IAM	Session allow/deny
operator.fido2_registered	Bool	IAM	Session requirement
operator.source_ip_hash	String	G1	Geo-blocking, anomaly
operator.source_country	String	GeolP	Geo-blocking
operator.active_sessions	Int	Session store	Concurrent limit
tenant.tier	Enum	Config	Feature gating
tenant.pqc_mandatory	Bool	Config	Crypto profile enforcement
tenant.blocked_countries	List	Policy	Geo-blocking
tenant.max_concurrent_sessions	Int	Policy	Session limit
session.crypto_profile	Enum	Negotiated	Crypto compliance
time.hour	Int	System	Time-of-day restrictions
device.certificate_valid	Bool	PKI/CRL	Device authentication

130.3 Admin privileges matrix.

Admin rola	Tenant scope	Operator access	Infra access	Crypto access	Audit access
SYLION SuperAdmin	All	Metadata only	Full	Full (HSM admin)	Full
SYLION Admin	Assigned	Metadata only	Read + deploy	Read	Full
SYLION SOC Analyst	Assigned	Metadata + session logs	Read	—	Full
Customer Tenant Admin	Own only	Full (own operators)	—	—	Own tenant
Customer Auditor	Own only	Read-only	—	—	Own tenant (read)

130.4 Tenant delegation matrix. Customer Tenant Admin może delegować do operatorów: (a) Team Lead: manage team members (provisioning, suspension), view team sessions, view team audit logs. (b) Support Operator: view other operator sessions (for support purposes), no modify. (c) Compliance Officer: view all tenant audit logs, export audit data, no operational access. Delegacja kaskadowa: Team Lead nie może delegować uprawnień, których sam nie posiada.

130.5 Incident response roles matrix.

Rola IR	P1 (Critical)	P2 (High)	P3 (Medium)	P4 (Low)
Incident Commander	CISO	SOC Lead	SOC Analyst	—
Technical Lead	CTO / Lead Architect	Sr. Platform Engineer	Platform Engineer	Support Engineer
Communications	CEO / VP Comms	Account Manager	Account Manager	—
Legal	General Counsel	Legal Advisor	—	—
Customer Liaison	Account Manager	Account Manager	Support	Support
SOC Analyst	2+ analysts	1 analyst	1 analyst	—
Platform Engineer	2+ engineers	1 engineer	as needed	—

130.6 Separation of duties matrix. Incompatible role combinations (one person CANNOT hold both):

Rola A	Rola B (incompatible)	Uzasadnienie
Code developer	Production deployer	No self-deploy

Change requester	Change approver	No self-approve
HSM key generator	HSM key auditor	No self-audit of keys
SOC analyst (investigator)	Subject of investigation	Conflict of interest
Vendor relationship manager	Vendor auditor	Independence
SuperAdmin	Auditor	Independence

130.7 Break-glass matrix.

Scenario	Who can initiate	Approval required	Max duration	Access granted	Audit
Tenant admin locked out	SOC Analyst	SOC Lead + CISO	2h	Tenant admin reset	Full
Platform-wide outage	Platform Engineer	CTO + CISO	4h	Full infrastructure	Full
Active compromise (P1)	SOC Analyst	SOC Lead (single)	1h	Isolation + forensic	Full
HSM emergency	CISO	CEO + CTO	1h	HSM admin operations	Full
Legal emergency disclosure	General Counsel	CEO	Per legal timeline	Specified data only	Full

Każdy break-glass: automatyczny alert do wszystkich C-level, time-bounded (auto-revoke po upływie), full audit trail (niemodyfikowalny), post-incident review mandatory.

Rozdział 131. Indeksy, mapowania i cross-reference

131.1 Indeks pojęć

Status: [R] Rekomendowany Odbiorca: Wszyscy Wpływ na baseline: Niski Powiązane rozdziały: 131.2, 131.3

Alfabetyczny indeks kluczowych pojęć zdefiniowanych w Księdze Systemu SYLION 3.0 (wybrane pozycje — pełny indeks generowany automatycznie):

Pojęcie	Definicja (skrót)	Pierwszy występ
Air-gap	Fizyczna izolacja sieci od internetu	119.2
Blind Broker	Session broker bez dostępu do treści mediów	124.1
Break-glass	Procedura awaryjnego dostępu z podwyższonymi uprawnieniami	130.7
CDR	Content Disarm & Reconstruction — sanityzacja plików	127.3
Certyfikowalny rdzeń	Część systemu objęta certyfikacjami (bez [A] i [E])	123.1
Confidential Computing	Ochrona danych w użyciu (RAM) via TEE	119.1
Dark-Matrix	Matrix homeserver jako Tor hidden service	124.3
Duress mode	Fałszywy profil aktywowany pod przymusem	121.5
E2EE	End-to-End Encryption — szyfrowanie end-to-end	115.2
Firecracker	Lightweight microVM monitor (AWS)	109.3
FIDO2	Standard autentykacji bezhasłowej (WebAuthn + CTAP)	125.1
G1 Gateway	Bramka dostępowa (Zone 1), terminacja IPsec	127.1
G2 Gateway	Bramka sesyjna (Zone 2), session broker	127.1
HSM	Hardware Security Module — moduł kryptograficzny	119.3
IKEv2	Internet Key Exchange version 2 (IPsec)	127.2
IMSI rotation	Zmiana tożsamości SIM w sieci komórkowej	123.4
Jurisdictional hopping	Routing przez wiele jurysdykcji	123.7
MicroVM	Lekka maszyna wirtualna (Firecracker)	109.3
ML-KEM	Module Lattice Key Encapsulation Mechanism (PQC)	119.3
ML-DSA	Module Lattice Digital Signature Algorithm (PQC)	119.3
No-data-on-terminal	Zasada: brak danych na urządzeniu końcowym	115.2
OPA	Open Policy Agent — silnik polityk	125.3
Operator	Użytkownik końcowy SYLION (osoba korzystająca z platformy)	130.1
PQC	Post-Quantum Cryptography	116.7
SFrame	Secure Frame (RFC 9605) — E2EE dla WebRTC	124.1
Sovereign deployment	Wdrożenie z pełną izolacją jurysdykcyjną	119.6
Thin Client	Model: terminal nie przechowuje danych	115.2
Zero Trust	Architektura: nigdy nie ufaj, zawsze weryfikuj	127.2
Zone (Strefa)	Segment bezpieczeństwa SYLION (0-5)	127.1

131.2 Indeks skrótów

Poniższy indeks zawiera kluczowe akronimy stosowane w Księdze Systemu SYLION 3.0, pogrupowane tematycznie. Pełne definicje znajdują się w Rozdziale 5 (Słownik pojęć). ADR — Architecture Decision Record. ABAC — Attribute-Based Access Control. BPM — Business Process Management. CA — Certificate Authority. CDR — Content Disarm and Reconstruction. CISO — Chief Information Security Officer. CNSA — Commercial National Security Algorithm. CSfC — Commercial Solutions for Classified. DMS — Dead Man's Switch. DORA — Digital Operational Resilience Act. DR — Disaster Recovery. E2EE — End-to-End Encryption. EID — eUICC Identifier. FIDO2 — Fast Identity Online 2. FIPS — Federal Information Processing Standards. G1 — Network Gateway (Brama Sieciowa). G2 — Access Broker (Broker Dostępu). GDPR — General Data Protection Regulation. HSM — Hardware Security Module. IaC — Infrastructure as Code. IAM — Identity and Access Management. IKEv2 — Internet Key Exchange version 2. IMEI — International Mobile Equipment Identity. IMSI — International Mobile Subscriber Identity. IPsec — Internet Protocol Security. IR — Incident Response. MFA — Multi-Factor Authentication. ML-KEM — Module-Lattice-Based Key Encapsulation Mechanism. MLS — Messaging Layer Security. MTTR — Mean Time to Recover. NIS2 — Network and Information Systems Directive 2. OPA — Open Policy Agent. PKI — Public Key Infrastructure. PQC — Post-Quantum Cryptography. RBAC — Role-Based Access Control. RFC — Request for Comments. RPO — Recovery Point Objective. RSD — Requirements and Security Document. RTO — Recovery Time Objective. SEV-SNP — Secure Encrypted Virtualization-Secure Nested Paging. SIEM — Security Information and Event Management. SLA — Service Level Agreement. SLO — Service Level Objective. SML — SYLION Maturity Level. SOAR — Security Orchestration Automation and Response. SOC — Security Operations Center. SRE — Site Reliability Engineering. TDX — Trust Domain Extensions. TEE — Trusted Execution Environment. ZTNA — Zero Trust Network Access.

Status: [R] Rekomendowany Odbiorca: Wszyscy Wpływ na baseline: Niski Powiązane rozdziały: 131.1

Skrót	Rozwinięcie	Kontekst	Pierwszy występ
ABAC	Attribute-Based Access Control	Authorization	130.2
AES	Advanced Encryption Standard	Symmetric crypto	119.3
AMER	Autonomous Module Exception Record	Compliance	123.10
BTS	Base Transceiver Station	Telecom	123.6
CA	Certificate Authority	PKI	129.1
CC	Common Criteria (ISO 15408)	Certification	116.4
CDR	Content Disarm & Reconstruction	Security	127.3
CMMC	Cybersecurity Maturity Model Certification	US DoD	121.8
CNSA	Commercial National Security Algorithm Suite	Crypto	116.7
CRL	Certificate Revocation List	PKI	126.1
CSIRT	Computer Security Incident Response Team	Operations	121.10
CUI	Controlled Unclassified Information	US classification	116.6
DCT	Discrete Cosine Transform	Watermarking	124.2
DISA	Defense Information Systems Agency	US DoD	116.6
DORA	Digital Operational Resilience Act	EU regulation	121.1
DPA	Data Protection Authority	GDPR	117.6
DPIA	Data Protection Impact Assessment	GDPR	115.8
E2EE	End-to-End Encryption	Security	115.2
EAL	Evaluation Assurance Level	CC	116.4
ECCN	Export Control Classification Number	Export	114.6
EID	Embedded Identity Document (eSIM)	Telecom	123.4
FIDO2	Fast Identity Online 2 (WebAuthn + CTAP)	Auth	125.1
FIPS	Federal Information Processing Standard	US standard	116.3
FL	Federated Learning	AI/ML	122.2
GDPR	General Data Protection Regulation	EU privacy	115.1
HSM	Hardware Security Module	Crypto	119.3
IaC	Infrastructure as Code	DevOps	113.1
IKEv2	Internet Key Exchange version 2	IPsec	127.2
IL	Impact Level (DISA)	US DoD	116.6
IMEI	International Mobile Equipment Identity	Telecom	123.9
IMSI	International Mobile Subscriber Identity	Telecom	123.4
IPsec	Internet Protocol Security	Network	127.2
MLAT	Mutual Legal Assistance Treaty	Legal	119.5
ML-DSA	Module-Lattice Digital Signature Algorithm	PQC	119.3
ML-KEM	Module-Lattice Key Encapsulation Mechanism	PQC	119.3
MLS	Messaging Layer Security	Protocol	124.1
mTLS	Mutual TLS	Auth	125.1

MVNO	Mobile Virtual Network Operator	Telecom	123.4
NIS2	Network and Information Security Directive 2	EU regulation	117.6
OPA	Open Policy Agent	Policy	125.3
PQC	Post-Quantum Cryptography	Crypto	116.7
QKD	Quantum Key Distribution	Quantum	124.6
QRNG	Quantum Random Number Generator	Quantum	124.6
RBAC	Role-Based Access Control	Authorization	130.1
RTO	Recovery Time Objective	DR	117.1
RPO	Recovery Point Objective	DR	117.1
SFU	Selective Forwarding Unit (WebRTC)	Media	124.1
SLA	Service Level Agreement	Contract	117.1
SOC	Security Operations Center	Operations	119.4
S RTP	Secure Real-time Transport Protocol	Media	124.5
TEE	Trusted Execution Environment	Confidential Computing	119.1
WORM	Write Once Read Many	Storage	111.7

131.3 Indeks komponentów

Indeks komponentów systemu SYLION 3.0 z odniesieniami do rozdziałów definiujących ich wymagania. env-browser (Środowisko przeglądarki) — Rozdz. 32–51. env-matrix (Środowisko Matrix) — Rozdz. 32–51. env-office (Środowisko biurowe) — Rozdz. 32–51. env-signal (Środowisko Signal) — Rozdz. 32–51. env-voice (Środowisko głosowe/wideo) — Rozdz. 32–51. Firecracker MicroVM — Rozdz. 24–31. G1 Network Gateway — Rozdz. 24–31. G2 Access Broker — Rozdz. 24–31. GrapheneOS Terminal — Rozdz. 17–23. HSM / PKI — Rozdz. 72–78. IPsec IKEv2 (strongSwan) — Rozdz. 24–31, 72–78. Matrix Synapse Homeserver — Rozdz. 32–51. Mudi v2 Router (GL-E750V2) — Rozdz. 17–23. OPSWAT Deep CDR — Rozdz. 62–71. AMD SEV-SNP / Intel TDX — Rozdz. 32–51. SIEM / Monitoring — Rozdz. 85–90. VPS Operatora — Rozdz. 32–51.

Status: [R] Rekomendowany Odbiorca: Architekt | Dev | Infra Wpływ na baseline: Średni Powiązane rozdziały: 131.1, 131.4

Komponent	Strefa	Tier: STD/PRO/STATE	Kluczowe rozdziały
Pixel Terminal (GrapheneOS)	0	✓/✓/✓	121.5, 123.4, 127.1
GL-iNet Router	0	✓/✓/✓	123.8, 127.1
FIDO2 Key (biometric)	0	✓/✓/✓	125.1, 127.2
G1 Gateway	1	Shared/Shared/Dedicated	110.2, 120.6, 127.1
G2 Session Broker	2	Shared/Shared-Ded/Dedicated	124.1, 127.1, 128.5
CDR Engine	2/4	✓/✓/✓	127.3, 128.1
Firecracker MicroVM	3	✓/✓/✓ (TEE for STATE)	109.3, 119.2, 127.1
Matrix Homeserver	4	Optional/Optional/Dedicated	119.6, 124.3
SIEM / Log Store	4	Shared/Shared/Dedicated	111.7, 116.9, 129.1
Monitoring (Prometheus)	4	Shared/Shared/Dedicated	128.6, 129.1
IAM Service	5	✓/✓/✓	125.1, 127.2, 130.1
PKI / HSM	5	Shared/Partition/Dedicated	116.3, 119.3
Policy Engine (OPA)	5	✓/✓/✓	125.3, 128.4
Config Management	5	✓/✓/✓	113.1, 128.2

131.4 Indeks procedur

Indeks procedur operacyjnych z odniesieniami do rozdziałów-źródeł. Disaster Recovery (DR) — Rozdz. 84. Dead Man's Switch (aktywacja i obsługa) — Rozdz. 79–84. Forensics — zbieranie dowodów — Rozdz. 98–104. IMSI rotation (moduł autonomiczny) — Rozdz. 123. Incident Response (IR) — Rozdz. 98–104. Key Ceremony (HSM/PKI) — Rozdz. 72–78. Onboarding operatora — Rozdz. 79–84. Offboarding operatora (revoke) — Rozdz. 79–84. Panic Button / Duress PIN — Rozdz. 17–23. Provisioning środowiska — Rozdz. 109–113. Re-enrollment FIDO2 (awaryjny) — Rozdz. 17–23. Rebuild środowiska po incydencie — Rozdz. 98–104. Rotacja certyfikatów — Rozdz. 72–78. Rotacja sekretów — Rozdz. 62–71.

Status: [R] Rekomendowany Odbiorca: SOC | Infra | Compliance Wpływ na baseline: Średni Powiązane rozdziały: 126.1–126.6, 129.1–129.8

Procedura	Typ	ID Playbooka	Rozdział
Terminal loss/theft response	Security	PB-SEC-001	126.1, 126.3
Workload compromise response	Security	PB-SEC-002	126.3
Legal seizure request	Legal	PB-LEGAL-001	126.3
Region failover	Infrastructure	PB-INFRA-001	126.4
Customer onboarding	Operations	PB-OPS-001	126.5

Customer offboarding	Operations	PB-OPS-002	126.5
Upgrade/rollback	Infrastructure	PB-INFRA-003	126.6
Break-glass activation	Security	130.7	130.7
Certificate rotation	Operations	—	129.1
Key ceremony	Security	—	119.6
DR exercise	Operations	—	119.4
Incident notification	Compliance	—	117.6
Risk exception	Compliance	—	118.7, 129.6
Change request	Operations	—	117.8, 129.7
Autonomous module activation	Compliance	—	123.10

131.5 Mapowanie rozdziałów do ról

Status: [R] Rekomendowany Odbiorca: Wszyscy Wpływ na baseline: Niski Powiązane rozdziały: 131.6, 131.7

Matryca: które rozdziały (109–131) są wymagane (W), rekomendowane (R), lub informacyjne (I) dla każdej roli czytelnika.

Rozdział	Zarząd	Architekt	Dev	Infra	SOC	Compliance	Sales	Klient
109 Wzorce wdrożeniowe	I	W	R	W	I	I	I	—
110 Sieć multi-region	I	W	R	W	R	I	I	—
111 Storage/DB	—	W	R	W	I	I	—	—
112 Koszty/FinOps	W	R	—	R	—	I	W	I
113 Terraform/IaC	—	R	R	W	I	I	—	—
114 Ramy prawne	W	R	I	I	I	W	W	R
115 Ochrona danych	R	R	I	I	I	W	R	W
116 Audyty/certyfikacje	W	R	I	I	I	W	W	R
117 SLA/umowy	W	I	—	I	R	W	W	W
118 Zarządzanie ryzykiem	W	R	I	I	R	W	I	I
119 State-level	R	W	R	W	W	W	W	W
120 Enterprise multi-tenant	I	W	R	W	R	R	R	R
121 Scenariusze branżowe	R	R	I	I	I	R	W	W
122 AI/edge/FL	I	R	R	R	R	I	I	—
123 Moduły autonomiczne	R	W	R	R	R	W	W	W
124 Moduły eksperymentalne	I	W	R	R	R	R	R	I
125 Szablony API	—	W	W	R	I	—	—	—
126 Playbooki	I	R	I	W	W	R	—	I
127 Diagramy	I	W	R	R	R	I	I	I
128 CI/CD/IaC	—	R	W	W	I	I	—	—
129 Checklisty	I	R	I	W	W	W	I	R
130 Matryce ról	R	W	R	R	W	W	I	R
131 Indeksy	I	R	R	R	R	R	R	R

131.6 Mapowanie rozdziałów do lifecycle produktu

Status: [R] Rekomendowany Odbiorca: PM | Architekt Wpływ na baseline: Niski Powiązane rozdziały: 131.5

Rozdział	Design	Build	Test	Deploy	Operate	Respond
109 Wzorce wdrożeniowe	★	★	—	★	—	—
110 Sieć multi-region	★	★	—	★	●	—
111 Storage/DB	★	★	—	★	●	—
112 Koszty/FinOps	★	—	—	—	★	—
113 Terraform/IaC	●	★	★	★	●	—
114 Ramy prawne	★	●	—	●	●	●
115 Ochrona danych	★	★	●	●	★	●
116 Audyty	●	—	●	—	★	●
117 SLA/umowy	★	—	—	●	★	★

118 Zarządzanie ryzykiem	★	●	—	—	★	★
119 State-level	★	★	★	★	★	★
120 Enterprise	★	★	●	★	●	—
121 Scenariusze	★	●	●	●	●	●
122 AI/edge	★	★	★	●	●	—
123 Moduły [A]	★	★	★	★	★	★
124 Moduły [E]	★	★	★	●	●	—
125 Szablony API	★	★	★	—	—	—
126 Playbooki	—	—	★	★	★	★
127 Diagramy	★	●	—	—	—	—
128 CI/CD	—	★	★	★	●	—
129 Checklisty	—	—	★	★	★	★
130 Matryce	★	★	—	★	★	★
131 Indeksy	●	●	●	●	●	●

★ = primary relevance, ● = secondary relevance.

131.7 Mapowanie rozdziałów do certyfikacji i kontroli

Mapowanie rozdziałów Księgi na kontrole i wymagania kluczowych certyfikacji. ISO 27001:2022 — Rozdz. 1–7 (polityki i zakres), 62–71 (kontrola dostępu, szyfrowanie), 85–90 (monitoring), 114–118 (compliance). FIPS 140-3 — Rozdz. 72–78 (moduły kryptograficzne, HSM). Common Criteria EAL4+ — Rozdz. 24–31 (architektura Split Gateway), 32–51 (izolacja workloadów), 62–71 (polityki bezpieczeństwa). FedRAMP (Low/Moderate) — Rozdz. 24–31, 62–71, 79–84, 85–90, 114–118. CNSA 2.0 — Rozdz. 72–78 (ML-KEM, ML-DSA, IPsec IKEv2). NIS2 — Rozdz. 79–84 (ciągłość działania), 98–104 (zarządzanie incydentami), 114–118. GDPR — Rozdz. 115 (ochrona danych), 116 (audyty), 118 (zarządzanie ryzykiem). DORA — Rozdz. 79–84, 84 (DR/BCP), 114–118.

Status: [R] Rekomendowany Odbiorca: Compliance | Auditor Wpływ na baseline: Wysoki Powiązane rozdziały: 116.1–116.6, 118.4

Framework / Kontrola	Kluczowe rozdziały SYLION
ISO 27001:2022	
A.5 Organizational controls	114, 117, 118
A.5.2 Information security roles	130.1, 130.6
A.5.23 Cloud services security	109, 110, 111
A.5.29 Security during disruption	126.4, 119.4
A.6 People controls	129.1 (training)
A.7 Physical controls	119.2 (on-prem)
A.8.1 User endpoint devices	121.5 (Pixel/terminal)
A.8.5 Secure authentication	125.1 (FIDO2), 130.1
A.8.9 Configuration management	113, 128.2
A.8.15 Logging	111.7, 125.4, 116.9
A.8.24 Use of cryptography	119.3, 116.7
A.8.25 SDLC security	128.1
A.8.28 Secure coding	128.1 (SAST)
SOC 2	
CC6 (Logical/physical access)	130.1, 120.4, 119.2
CC7 (System operations)	126, 129.1
CC8 (Change management)	113, 128.1, 117.8
CC9 (Risk mitigation)	118.1–118.4
A1 (Availability)	110, 117.1, 119.4
C1 (Confidentiality)	111.6, 119.3, 115
CNSA 2.0	
ML-KEM-1024 requirement	119.3, 116.7
ML-DSA-87 requirement	119.3, 128.1 (signing)
AES-256 requirement	111.6, 119.3
SHA-384+ requirement	119.3, 125.5
PQC-only by 2030	116.7 roadmap
FedRAMP	

AC (Access Control)	130.1, 120.4
AU (Audit)	125.4, 116.9, 111.7
CM (Configuration Management)	113, 128.2
CP (Contingency Planning)	126.4, 119.4
IA (Identification/Authentication)	125.1 (FIDO2), 130.1
IR (Incident Response)	126.3, 117.6, 129.5
SC (System/Comms Protection)	110, 119.3, 120.7

131.8 Mapowanie rozdziałów do tierów

Status: [R] Rekomendowany Odbiorca: Sales | PM | Klient Wpływ na baseline: Niski Powiązane rozdziały: 117.2, 119.1

Rozdział	STANDARD	PRO	STATE/SOVEREIGN
109 Wzorce wdrożeniowe	Containers + microVM	Containers + microVM	Dedicated + bare-metal + microVM
110 Sieć multi-region	Single region	Multi-region optional	Multi-region mandatory
111 Storage/DB	Standard encryption	Per-tenant keys	Dedicated HSM + storage
112 Koszty	400€/user	1500€/user	2500€/user
113 IaC	Standard modules	Standard + custom	Fully custom
114 Ramy prawne	GDPR, basic	GDPR, DORA-ready	Full regulatory
115 Prywatność	Standard PbD	Enhanced	Maximum + sovereign
116 Certyfikacje	Covered by platform cert	Covered + customer audits	Dedicated cert path
117 SLA	99.5%, 4h P1	99.9%, 1h P1	99.95%, 15min P1
118 Risk/compliance	Platform risk register	Per-tenant risk	Dedicated risk program
119 State-level	—	—	★ Full chapter
120 Enterprise	Basic tenant isolation	Enhanced isolation	Cluster-per-tenant
121 Scenariusze	General	Sector-specific	Sector + sovereign
122 AI/edge	—	Optional	Optional + custom
123 Moduły [A]	Available (limited)	Available	Available + custom
124 Moduły [E]	—	Available	Available + priority

Koniec Części XIV–XVII Księgi Systemu SYLION 3.0 (Rozdziały 109–131).

Następna aktualizacja: zgodnie z polityką wersjonowania (Rozdział 4).

CZĘŚĆ PHANTOM 4.0 — profil rozszerzony

PHANTOM 4.0 jest profilem wysokiego ryzyka. Nie jest pojedynczym modulem, lecz zestawem wymagań dla terminala, routera, G1, G2, workloadów, streamingu, CDR, rotacji, audytu i procedur. PHANTOM nie może automatycznie odblokowywać funkcji baseline bez human gate.

PHANTOM: warstwy

Warstwa	Cel	Mechanizm	Ryzyko rezydualne
Pixel	cienki terminal	GrapheneOS, profil CA, posture check, brak danych lokalnych	aktywny malware może widzieć bieżący ekran/wejście
Puli AX	kontrolowany WAN	VPN, kill switch, DNS leak prevention, pakiet routera	baseband/router firmware/supply chain
FIDO2	fizyczna obecność operatora	touch/biometria, odnowienie sesji	procedury odzyskiwania i social engineering
G1	pierwsza brama	certyfikaty, VPN, posture gate	metadane i DoS
G2	broker sesji	limit sesji, routing, docelowo blind broker	jawny stream jeśli broker nie jest E2EE
Workload	izolacja aplikacji	Firecracker, dedykacja, rebuild	VM escape, kernel hosta, provider
CDR	kontrola plików	sanitize, quarantine, hash, audit	formaty nieobsłużone i błędy polityki
Blue team	wykrywanie naruszeń	metadane, anomalia, alerty, eBPF roadmap	brak treści oznacza ograniczenia diagnostyczne

PHANTOM: czego nie wolno twierdzić

- Nie wolno twierdzić, że system daje niewykrywalność albo anonimowość absolutną.
- Nie wolno twierdzić, że RF fingerprinting da się w pełni rozwiązać software'owo.
- Nie wolno twierdzić, że VPN chroni metadane operatora komórkowego.
- Nie wolno twierdzić, że G2 jest ślepy, dopóki streaming nie ma E2EE od mikroVM do terminala.
- Nie wolno uruchamiać funkcji RF/telecom jako zwykłych funkcji produktu.

PHANTOM: wymagania wdrożeniowe

Wymaganie	Test	Gate
Pixel widzi G1 tylko po przejściu posture policy	ADB human regression + negative test bez routera/FIDO2	CISO/Architect
Puli AX wymusza tunel i kill switch	test DNS leak, route leak, reconnect, WAN loss	SRE/Security
G2 nie zapisuje streamu ani wejścia	log audit + storage negative test	Security
Workload recreate niszczy stan aplikacji	human test: zamknij, recreate, uruchom od zera	Platform
CDR działa dla plików	test upload/download/quarantine/sanitize	Security
Rotacja nie zostawia sekretów	cleanup evidence + new cert fingerprint + audit	SRE

CZĘŚĆ C — Indeks źródłowy PHANTOM v3.0

Indeks pokazuje pełną strukturę źródłowego dokumentu PHANTOM v3.0. Warstwa internal 4.0 rozdziela elementy produktowe, governance, lab-only i zewnętrzne restricted SOP.

Styl	Nagłówek źródłowy
Heading 1	1. Wprowadzenie i klasyfikacja dokumentu
Heading 2	1.1 Cel dokumentu
Heading 2	1.2 Relacja do Księgi SYLION 3.0
Heading 2	1.3 Kto może wdrożyć PHANTOM
Heading 1	2. Filozofia zerowego śladu
Heading 2	2.1 Zasada efemeryczności totalnej
Heading 2	2.2 Model zagrożenia PHANTOM
Heading 2	2.3 Czego PHANTOM NIE robi
Heading 1	3. Profil przeciwnika i model zagrożeń
Heading 2	3.1 Hierarchia sojuszy wywiadowczych
Heading 2	3.2 Możliwości zbierania danych (collection capabilities)
Heading 2	3.3 Zdolności forensic i ekstrakcji
Heading 1	4. Pełna macierz scenariuszy ataku
Heading 2	4.1 Warstwa telekomunikacyjna (poniżej VPN)
Heading 3	4.1.1 IMSI Catcher (CSS — Cell Site Simulator)
Heading 3	4.1.2 SS7/Diameter — ataki poniżej VPN
Heading 3	4.1.3 RRLP/LPP — wymuszona lokalizacja GPS
Heading 3	4.1.4 Silent SMS (Type 0)
Heading 3	4.1.5 Tower dump i retencja operatorów
Heading 3	4.1.6 Korelacja behawioralna (pattern-of-life)
Heading 2	4.2 Warstwa sieciowa i transportowa
Heading 3	4.2.1 DPI i identyfikacja tunelu IPsec
Heading 3	4.2.2 Analiza ruchu i korelacja czasowa
Heading 3	4.2.3 Atak baseband — zero-click RCE
Heading 2	4.3 Warstwa infrastruktury chmurowej
Heading 3	4.3.1 Kompromitacja dostawcy VPS
Heading 3	4.3.2 Cold boot attack na serwery
Heading 3	4.3.3 VM escape i hypervisor attacks
Heading 3	4.3.4 Certificate Transparency jako wektor korelacji
Heading 2	4.4 Warstwa terminala i urządzeń
Heading 3	4.4.1 Przejęcie fizyczne terminala
Heading 3	4.4.2 Evil maid — podmiana terminala
Heading 3	4.4.3 RF fingerprinting urządzenia
Heading 2	4.5 Warstwa ludzka i operacyjna
Heading 3	4.5.1 Kompromitacja personelu
Heading 3	4.5.2 Błąd operatora
Heading 3	4.5.3 Atak na łańcuch dostaw SIM/eSIM
Heading 1	5. Architektura efemerycznego stosu
Heading 2	5.1 Komponenty stosu PHANTOM
Heading 2	5.2 RAM-Only Operating System
Heading 2	5.3 Architektura stosu PHANTOM — diagram logiczny
Heading 1	6. Rotacja jurysdykcyjna całego stosu
Heading 2	6.1 Koncepcja rotacji
Heading 2	6.2 Pula jurysdykcji
Heading 2	6.3 Harmonogram rotacji
Heading 2	6.4 Procedura rotacji — krok po kroku

Heading 2	6.5 Gwarancja braku korelacji między inkarnacjami
Heading 1	7. Rotacja tożsamości urządzeń: eSIM, IMEI, MAC
Heading 2	7.1 Koncepcja pakietów rotacyjnych
Heading 2	7.2 Problem EID — dlaczego rotacja eSIM jest niewystarczająca
Heading 2	7.3 Dwupoziomowy system SIM dla PHANTOM
Heading 3	7.3.1 Poziom P1 (domyślny): Fizyczne karty SIM — całkowita eliminacja EID
Heading 3	7.3.2 Poziom P2 (alternatywny): Wymienne karty eUICC — rotacja EID przez wymianę chipów
Heading 3	7.3.3 Tabela porównawcza metod SIM
Heading 3	7.3.4 Wymagania sprzętowe routera PHANTOM
Heading 2	7.4 Pakiet MAC — rotacja adresów fizycznych
Heading 3	7.4.1 Mechanizm parowania MAC
Heading 3	7.4.2 IP Rotating z synchronizacją MAC
Heading 2	7.5 Tabela identyfikatorów rotacji — kompletne zestawienie
Heading 2	7.5b Synchronizacja z MAC — wielowarstwowa dekorelacja
Heading 2	7.6 Zarządzanie IMEI
Heading 2	7.6b Tabela częstotliwości rotacji identyfikatorów
Heading 2	7.6c Dostarczenie pakietów i onboarding
Heading 2	7.7 Kill switch — natychmiastowa izolacja
Heading 1	8. Pula eSIM w routerze — architektura, zagrożenia i zarządzanie
Heading 2	8.1 Koncepcja puli 5 000 profili eSIM
Heading 2	8.2 Zagrożenia inwigilacyjne eSIM vs fizyczna karta SIM
Heading 2	8.3 EID jako fundamentalny problem eSIM
Heading 2	8.4 Strategia mitygacji EID dla puli 5 000 profili
Heading 2	8.5 Zarządzanie pulą eSIM w routerze — operacje
Heading 2	8.6 Tabela częstotliwości rotacji per typ identyfikatora (z uwzględnieniem eSIM)
Heading 2	8.7 Routery DOPUSZCZALNE i NIEDOPUSZCZALNE dla puli eSIM
Heading 1	9. Pula 50 jurysdykcji rotacyjnych
Heading 2	9.1 Kryteria selekcji jurysdykcji
Heading 2	9.2 Pełna mapa jurysdykcji
Heading 2	9.3 Dostawcy VPS z crypto i hourly billing
Heading 1	10. Pula tysięcy kart SIM/eSIM
Heading 2	10.1 Kraje bez rejestracji SIM (lista 2025–2026)
Heading 2	10.2 Anonimowi dostawcy eSIM
Heading 2	10.3 Strategia puli tysięcy kart
Heading 1	11. Kryptograficzna izolacja operatorów
Heading 2	11.1 Model izolacji — dlaczego operatorzy są niepołączalni
Heading 2	11.2 Separacja prawna i jurysdykcyjna
Heading 2	11.3 Dowód izolacji — jak wykazać rozdzielenie
Heading 1	12. Mechanizmy niszczenia śladów
Heading 2	12.0 Pięć warstw niszczenia śladów
Heading 2	12.1 Crypto-erase przy rotacji
Heading 2	12.1b W2: Crypto-erase — niszczenie przez zniszczenie klucza
Heading 2	12.1c W3: Log TTL — ring buffer z automatycznym nadpisywaniem
Heading 2	12.1d W4: Session purge — czyszczenie metadanych sesji
Heading 2	12.1e W5: Full Stack Destroy — niszczenie przy rotacji
Heading 2	12.2 Dead Man Switch
Heading 2	12.3 Panic Button — natychmiastowe zniszczenie
Heading 2	12.4 Zero-knowledge provisioning
Heading 2	12.5 Sanityzacja logów
Heading 2	12.6 Forensic resistance — model zagrożenia
Heading 2	12.6b Forward Secrecy między inkarnacjami
Heading 2	12.7 Retained components — co JEST trwałe

Heading 1	13. Komunikacja w trybie PHANTOM
Heading 2	13.1 Matrix over Tor
Heading 2	13.2 E2EE — szyfrowanie end-to-end
Heading 2	13.3 Forward-only messaging
Heading 2	13.4 OOB (Out-of-Band) kanał awaryjny
Heading 1	14. Orchestrator PHANTOM
Heading 2	14.1 Rola Orchestratora
Heading 2	14.2 Sealed Master — HSM i Shamir Secret Sharing
Heading 2	14.3 API Orchestratora
Heading 2	14.3b Architektura przepływu kluczy
Heading 2	14.4 Redundancja i failover
Heading 1	15. Narzędzia kontr-inwigilacji
Heading 1	16. Konfiguracja operacyjna GrapheneOS dla PHANTOM
Heading 1	17. Wektory ataku i macierz obrony — synteza
Heading 2	17.1 Macierz obrony PHANTOM — kompletne zestawienie
Heading 2	17.1b Macierz kosztów i czasu ataku
Heading 2	17.2 Hierarchia obrony PHANTOM — warstwy
Heading 1	18. Hierarchia ryzyk rezydualnych
Heading 1	19. Ryzyka prawne i operacyjne
Heading 2	19.1 Analiza prawna
Heading 2	19.2 Odpowiedzialność organizacji
Heading 2	19.3 SYLION — odpowiedzialność dostawcy
Heading 1	20. Procedury operacyjne PHANTOM
Heading 2	20.1 Onboarding operatora
Heading 2	20.2 Codzienna rutyna operacyjna
Heading 2	20.3 Procedura rotacji manualnej
Heading 2	20.4 Procedura awaryjnej ewakuacji
Heading 1	21. Specyfikacja techniczna komponentów
Heading 2	21.1 G1 PHANTOM — Network Gateway
Heading 2	21.2 G2 PHANTOM — Access Broker
Heading 2	21.3 VPS Operatora PHANTOM
Heading 2	21.4 Router mobilny PHANTOM
Heading 2	21.5 Terminal operatora
Heading 1	22. Porównanie: SYLION STATE vs PHANTOM
Heading 1	23. Konkluzja dla decydentów
Heading 2	23.1 Wartość PHANTOM — co system rzeczywiście robi
Heading 2	23.2 Wektory bez mitygacji technicznej
Heading 2	23.3 Parametry operacyjne
Heading 2	23.3b Analiza kosztów-korzyści PHANTOM vs STATE
Heading 2	23.3c Harmonogram wdrożenia PHANTOM
Heading 2	23.4 Rekomendacja wdrożeniowa
Heading 1	Aneks A: Słownik terminów PHANTOM
Heading 1	Aneks B: Standardy i referencje
Heading 1	Aneks C: Checklisty OPSEC dla operatorów PHANTOM
Heading 2	C.1 Checklist przed każdą sesją operacyjną
Heading 2	C.2 Checklist po każdej sesji operacyjnej
Heading 2	C.3 Checklist przy zmianie lokalizacji fizycznej
Heading 2	C.4 Procedura wymiany karty SIM (Poziom P1)
Heading 2	C.5 Procedura przełączenia profilu eSIM (Poziom P2)
Heading 1	Aneks D: Parametry techniczne — zestawienie zbiorcze
Heading 2	D.1 Parametry kryptograficzne PHANTOM
Heading 2	D.2 Parametry sieciowe PHANTOM

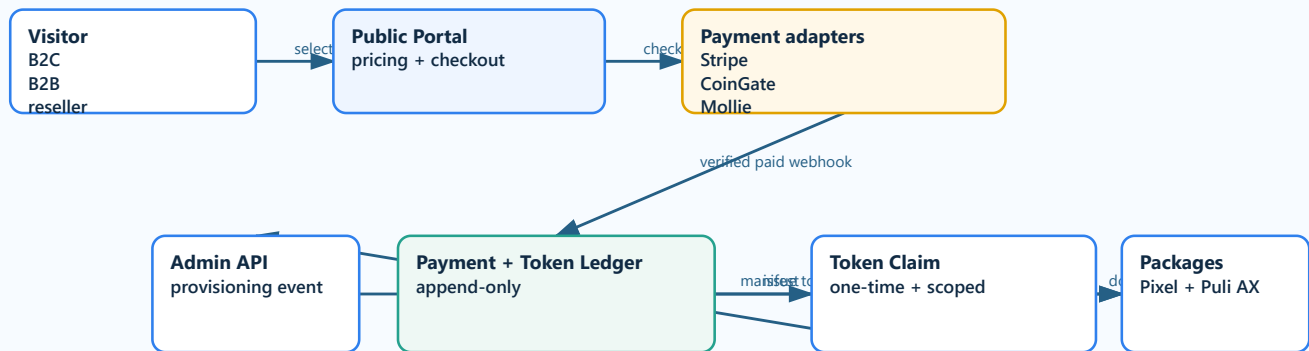
Heading 2	D.3 Minimalne wymagania sprzętowe
Heading 2	D.4 Koszt wdrożenia — zestawienie szczegółowe
Heading 1	Aneks E: Typowe scenariusze operacyjne PHANTOM
Heading 2	E.1 Scenariusz: Dziennikarz śledczy w kraju autorytarnym
Heading 2	E.2 Scenariusz: Kontrwywiad — operacja pod przykrywką
Heading 2	E.3 Scenariusz: Organizacja praw człowieka w strefie konfliktu

ZAŁĄCZNIK X - Portal zakupowy, płatności, tokeny i resellerzy

Ten aneks definiuje portal jako oddzielny publiczny moduł Zone 0. Portal sprzedaje tokeny i dodatki, obsługuje płatności oraz inicjuje bootstrap operatora, ale nie jest panelem administratora, panelem operatora ani brokerem streamingu. Portal ma być odseparowany sieciowo od G1/G2/workload stream i komunikować się z Admin API wyłącznie przez wąski, audytowany kanał provisioning/token.

X1. Portal zakupowy, płatność, token i bootstrap operatora

X1. Portal zakupowy, płatność, token i bootstrap operatora



X1. Perspektywy użytkownika i biznesu

Perspektywa	Cel	Funkcje portalu	Odzyskanie/obsługa	Granice prywatności
B2C privacy-first	Użytkownik prywatny kupuje token bez klasycznego konta klienta. Portal pokazuje tier, cenę roczną, dodatki, ograniczenia i ryzyka prywatności.	Zakup crypto lub karta/alternatywna metoda przez PSP, odbiór tokenu, wpisanie tokenu w claim flow, pobranie paczki Pixel/Puli AX albo aktywacja sprzętu od resellera.	Brak konta email-first. Odzyskanie dostępu przez recovery seed/operator wallet seed, jeżeli użytkownik go sam zapisał. Portal nie przechowuje seed.	Nie wolno obiecywać anonimowości. PSP, blockchain, bank albo reseller mogą posiadać własne dane i obowiązki prawne.
B2B company	Firma kupuje subskrypcję, chce fakturę, VAT, dane nabywcy, możliwość wielu tokenów i rozliczalność.	Wybór tieru, dane firmy, checkout/invoice, tokeny dla operatorów, panel rozliczeniowy albo eksport faktur.	Odzyskanie przez firmowy proces finansowy i uprawnionego reprezentanta, nie przez prywatny seed operatora.	B2B ma więcej danych osobowych/firmowych i dłuższą retencję księgową. Prywatność jest mniejsza niż w ścieżce crypto/private.
Reseller	Partner kupuje pule tokenów z rabatem, może sprzedawać skonfigurowany Pixel/Puli AX i przekazać paczki startowe.	Reseller console: batch order, rabat 20%, inventory tokenów, status unclaimed/claimed/expired, download paczek tylko dla tokenów przypisanych.	Reseller nie zna sekretów operatora, FIDO2, HSM ani recovery seed klienta. Może mieć tylko dane handlowe i sprzętowe.	Wymaga umowy, KYC/KYB resellera, limitów, audytu i możliwości odcięcia puli tokenów przy nadużyciu.
Admin / finance	Zespół wewnętrzny rozlicza płatności, webhooks, tokeny, resellerów, faktury i spójność z provisioningiem.	Monitoring płatności, reconciliation, ręczne oznaczenie sporu, revoke unclaimed token, retry webhook, export księgowy.	Admin nie widzi pełnych danych kart, seedów, prywatnych kluczy ani sekretów operatora.	Każda ręczna ingerencja w token albo płatność wymaga WORM audit i powiązania z payment event.

X2. Bramki płatności i model adapterów

Provider	Rola	Zakres	Kontrole	Uwagi
Stripe	Główna bramka kart, walletów i metod lokalnych; używać Stripe Checkout/Payment Element i oficjalnych webhooków.	Karty, portfele i lokalne metody zależne od kraju, waluty i konfiguracji konta. Stablecoin/crypto tylko jeśli dostępne po onboardingu i prawnie zatwierdzone.	Webhook signature verification, idempotency key, fetch payment/session from Stripe API before token mint.	Nie przechowywać danych kart w SYLION. PCI scope ma pozostać po stronie Stripe-hosted UI.
CoinGate	Primary crypto payment adapter dla BTC/ETH/LN/stablecoin i innych walut obsługiwanych przez providera.	Crypto checkout/order API, statusy płatności, settlement zgodnie z konfiguracją merchant.	Callback/webhook verification, paid/confirmed status, exchange-rate lock window, under/overpayment handling.	Crypto nie oznacza pełnej anonimowości. Blockchain i provider mogą umożliwiać korelację i compliance review.
Mollie	Backup PSP dla UE i metod lokalnych, szczególnie gdy Stripe jest niedostępny albo wymagana jest metoda lokalna.	Hosted checkout, karty, przelewy i metody regionalne zależne od kraju i aktywacji.	Webhook + API status verification, idempotency, payment state machine.	Mollie jest fallback, ale nie może generować innego tokenu dla tego samego order bez ledger lock.
Manual/invoice wire	Opcja B2B enterprise, gdy firma wymaga faktury pro-forma, przelewu lub procurement process.	Token generowany dopiero po ręcznym/księgowym potwierdzeniu płatności albo po zatwierdzonej polityce kredytu.	Four-eyes dla ręcznego paid override, dokument księgowy, WORM audit.	Nie używać dla B2C automatycznego self-service bez procedury antyfraud.

X3. Typy tokenów

Typ tokenu	Cel	Scope	Użycie	Efekt
BOOTSTRAP	Pierwsze utworzenie operatora.	tier, okres minimum 12 miesięcy, limity aplikacji, entitlement rotacji, provider policy, hardware package policy.	Jednorazowy. Po claimie przechodzi w provisioning_pending/active.	Tworzy operatora, G1/G2, workload plan, paczki Pixel/Puli AX i stan pierwszego logowania.
RENEWAL	Przedłużenie subskrypcji.	operator_id albo recovery identity, okres, cena, data ważności.	Jednorazowy, możliwy tylko dla istniejącego operatora.	Wydłuża expiry, nie zmienia tieru ani infrastruktury poza billing state.
UPGRADE	Podniesienie tieru.	old_tier, new_tier, cost delta, nowe limity, wymagane migracje zasobów.	Jednorazowy, wymaga symulacji kosztu i capacity przed apply.	Uruchamia zmianę entitlement i opcjonalną migrację workload/puli.
ADDON_JURISDICTION	Dokupienie rotacji, kraju albo capacity.	kraje, częstotliwość, provider allowlist, liczba rotacji lub okres.	Zużywalny albo okresowy, zależnie od produktu.	Zwiększa policy rotacji w panelu operatora bez zmiany bazowego tieru.

ADDON_APP_CAPACITY	Dokupienie dodatkowych środowisk aplikacyjnych.	liczba środowisk, app families, tryb desktop/native, okres.	Okresowy, powiązany z subskrypcją.	Zwiększa quota w Workload Control.
RESELLER_BATCH	Pula kodów dla resellera.	reseller_id, discount, liczba tokenów, tier allowlist, expiry, hardware bundle flag.	Tokeny potomne jednorazowe; batch ma limit i reconciliation.	Reseller wydaje token klientowi lub wiąże token ze skonfigurowanym sprzętem.
HARDWARE_BUNDLE	Token sprzętowy dla Pixela/Puli AX sprzedanego przez resellera.	device_batch_id, package profile, tier allowlist, reseller_id.	Jednorazowy, wiąże claim ze sprzętem/paczką.	Pozwala klientowi aktywować profil bez ujawniania sekretów resellerowi.
SERVICE_RECOVERY	Kontrolowane odzyskanie albo support flow.	scope, operator/recovery identity, expiry krótkie, support case.	Krótko żyjący, wymaga ręcznej autoryzacji.	Nie może omijać FIDO2/HSM ani panic policy.

X4. Lifecycle tokenu i płatności

Stan	Opis	Dowody/metadane	Reguła
quoted	Użytkownik wybrał tier/dodatki. Nie istnieje token.	quote_id, price, currency, tax estimate	Quote expires.
payment_pending	Order utworzony u PSP.	order_id, provider, provider_session_id	No token yet.
paid_unverified	Webhook deklaruje płatność, ale system jeszcze nie wykonał API fetch.	webhook_id, signature status	No token mint before verification.
paid_verified	Provider API potwierdził finalny paid/confirmed status.	provider status, amount, currency, idempotency key	Token mint allowed.
token_issued	Token wygenerowany i pokazany/pobrany raz.	token_id, token_hash, type, scope, expiry	Plaintext token not stored.
claim_started	Użytkownik wpisał token.	claim_id, device/browser metadata, risk score	Rate limit and anti-bruteforce.
claimed	Token związany z recovery identity/operator identity.	claim timestamp, public recovery id	Token cannot be reused.
provisioning_pending	Admin API dostał bootstrap event.	plan_id, package manifest	Async provisioning.
active	Operator działa albo subskrypcja została zmieniona.	operator_id, entitlement version	Audit event.
expired/revoked	Token nieaktywny.	reason, actor, time	Rejected on claim.

X5. Bezpieczeństwo tokenów

Kontrola	Wymaganie	Dlaczego
Format	Token jest opaque secret: losowy materiał >= 256 bitów plus publiczny prefix i checksum dla UX. Entitlement nie jest kodowany jako prawda w samym tokenie.	Atakujący nie może odgadnąć ani zmienić tieru przez edycję tokenu.
Storage	Baza przechowuje tylko token_hash z pepper/HMAC po stronie serwera, publiczny token_id, typ, scope i status.	Wyciek bazy nie daje tokenów do użycia.
Display	Plaintext token pokazany tylko raz po opłaceniu albo w paczce resellera. Potem możliwe jest tylko revoke/regenerate.	Ogranicza wycieki przez panel admina i support.
Claim	Claim wymaga rate limit, proof-of-work/CAPTCHA gdzie legalne, risk scoring, device binding i jednoznacznego locka transakcyjnego.	Chroni przed brute force, replay i race condition.
Webhook	Każdy payment webhook wymaga weryfikacji podpisu, raw body, timestamp tolerance, idempotency i ponownego odczytu statusu z API providera.	Chroni przed sfałszowanym paid event.
Ledger	Token events, payment events, claim events i provisioning events są zapisywane w append-only ledger/WORM audit.	Pozwala rozliczyć fraud, support i spory bez ujawniania sekretów.
Package binding	Paczka Pixel/Puli AX ma package_manifest, hash, signature i powiązanie z token claim/operator identity.	Chroni przed podmianą paczki startowej.
Recovery seed	Recovery seed/operator wallet seed jest generowany i trzymany przez użytkownika. Portal przechowuje tylko pochodny publiczny recovery identifier.	Brak klasycznego konta nie oznacza braku odzyskania, ale utrata seed może być nieodwracalna.

X6. UI/UX portalu

Widok	Zawartość	Akcje	Wymóg
Landing/pricing	Pierwszy ekran pokazuje ofertę, porównanie tierów, ceny roczne, minimum 12 miesięcy, limity aplikacji, rotacje, dedicated rules.	CTA: Buy private, Buy as company, Reseller portal, Redeem token.	Zero marketingowych obietnic anonimowości. Jasne residual risks i legal wording.
Tier configurator	Karty Pilot/Standard/Pro/Phantom/Sovereign, add-ons, liczba środowisk, rotacje, Matrix, hardware bundle.	Dynamiczny koszt: subskrypcja, dodatki, hardware, szacunkowy koszt utrzymania infrastruktury.	Phantom/Sovereign mogą wymagać verification gate przed finalną aktywacją.
Payment choice	Stripe/Mollie dla fiat, CoinGate dla crypto, manual invoice dla B2B.	Każda metoda pokazuje prywatność, retencję, settlement time, ryzyka i dostępność.	Nie generować tokenu przed verified paid.
Token delivery	Po płatności użytkownik widzi token tylko raz, może pobrać zaszyfrowany receipt/package manifest i instrukcję claim.	Opcja zapisania recovery seed i test zapisu seed przez użytkownika.	Portal nie odzyska seed ani plaintext tokenu.
Redeem/claim token	Pole wpisania tokenu, weryfikacja statusu, wybór trybu: mam sprzęt od resellera / pobierz paczki / aktywuj z Pixel.	Po claim: provisioning status, paczka Pixel, paczka Puli AX, QR/deep link, status G1/G2/workload.	Nie pokazywać publicznie 127.0.0.1 jako adresu produkcyjnego.
Reseller console	Login resellera, batch tokenów, rabat, urzędzenia, statusy, zwroty nieclaimed, eksport rozliczeń.	Reseller może widzieć stan handlowy, ale nie może wejść w operator panel klienta.	Każdy batch ma limit, expiry, audit i możliwość revoke.
B2B billing	Dane firmy, VAT, faktury, purchase order, wielokrotne tokeny, role finansowe.	Firma może zarządzać zakupami, ale nie treścią operatorów.	Retencja księgowa zgodna z jurysdykcją i polityką prywatności.

X7. Prywatność, B2C, B2B i crypto

Ścieżka	Co wie SYLION	Co może wiedzieć strona trzecia	Wording
B2C crypto	Minimalne dane portalu, brak klasycznego konta, token/recovery seed.	CoinGate i blockchain mogą przetwarzać lub ujawniać metadane płatności.	Nie obiecujemy anonimowości; obiecujemy minimalizację danych w SYLION i jawne granice.
B2C fiat	Portal może nie wymagać konta, ale PSP przetwarza dane płatności.	Stripe/Mollie/bank mogą mieć dane karty, IP, kraj, fraud signals.	SYLION nie przechowuje danych kart i używa hosted checkout.
B2B	Dane firmy, faktury, VAT, kontakty finansowe.	Retencja prawna/księgowa dłuższa niż B2C privacy-first.	Oddzielić finance account od operator identity.
Reseller	Reseller może znać klienta, sprzęt, numer zamówienia i token status.	Reseller nie zna FIDO2/HSM/recovery seed/operator secrets.	Umowa resellerska musi wymagać privacy handling i breach notification.
Analytics	Tylko techniczne metryki, consent-aware analytics, bez tracking pixel do reklam.	Ryzyko korelacji marketingowej i wycieku referrer.	Preferować self-hosted analytics i krótką retencję.

X8. Minimalny model danych

Tabela/encja	Pola	Zakaz
orders	order_id, channel, customer_type, tier, amount, currency, status	Nie trzymać plaintext tokenu.

payment_attempts	provider, provider_session_id, status, webhook_id, amount, currency	Webhook raw payload tylko jeśli retention/legal pozwala; redakcja sekretów.
tokens	token_id, token_hash, type, scope, tier, expiry, status, reseller_id	Hash + pepper/HMAC; no plaintext.
token_claims	claim_id, token_id, recovery_public_id, device posture, risk score, timestamp	Bez seed, bez hasel.
entitlements	operator_id, tier_version, quotas, rotation policy, addon flags	Wersjonować policy.
packages	package_id, operator_id/token_id, manifest_hash, signature, device profile	Paczki podpisane; download short TTL.
resellers	reseller_id, agreement status, discount, limits, KYB status	No operator secrets.
audit_events	actor, action, object, before/after safe diff, time, reason	Append-only/WORM.

X9. Kryteria odbioru portalu

Obszar	Warunek przejścia	Test
Payment webhooks	Forged webhook denied; replay denied; valid paid creates exactly one token.	automated integration test
Token brute force	Random token guessing is rate-limited and never reveals whether prefix exists beyond generic error.	negative security test
Double claim	Two concurrent claims result in one success and one deterministic deny.	race test
Reseller limit	Reseller cannot exceed batch quota or create unsupported tier token.	RBAC/quota test
B2B invoice	Invoice order can create token only after approved payment state.	finance workflow test
Crypto status	Underpaid/expired/unconfirmed crypto order does not mint token.	CoinGate sandbox/status test
Package integrity	Modified Pixel/Puli package is rejected by signature/hash check.	tamper test
Privacy	No card data, seed, plaintext token or provider secret appears in logs/admin UI.	log grep + UI inspection
Portal isolation	Portal VPS cannot reach operator stream/admin routes except narrow token/provisioning API.	network negative test

X10. Źródła adapterów płatności

Źródła sprawdzone na potrzeby aneksu w dniu 2026-06-01. Warunki dostępności metod płatności i crypto zależą od onboardingu merchant, jurysdykcji, walut, risk review i aktualnych zasad providera.

Provider	Zakres źródła	URL
Stripe	Payment methods and webhooks	https://docs.stripe.com/payments/payment-methods/overview ; https://docs.stripe.com/webhooks
CoinGate	Crypto payment API/callbacks/status	https://developer.coingate.com/
Mollie	Payments API, hosted checkout, webhooks	https://docs.mollie.com/

X11. Szczegółowe perspektywy portalu

Poniższe karty rozwijają funkcjonalność portalu z punktu widzenia faktycznych użytkowników i zespołów operacyjnych. Każda perspektywa ma oddzielne testy, bo portal prywatny, B2B i resellerowski mają różne dane, ryzyka i ścieżki odzyskania.

Perspektywa portalu: B2C privacy-first

Cel biznesowy
Użytkownik prywatny kupuje token bez klasycznego konta klienta. Portal pokazuje tier, cenę roczną, dodatki, ograniczenia i ryzyka prywatności.

Funkcjonalność wymagana w UI
Zakup crypto lub karta/alternatywna metoda przez PSP, odbiór tokenu, wpisanie tokenu w claim flow, pobranie paczki Pixel/Puli AX albo aktywacja sprzętu od resellera.

Obsługa i odzyskanie
Brak konta email-first. Odzyskanie dostępu przez recovery seed/operator wallet seed, jeżeli użytkownik go sam zapisał. Portal nie przechowuje seed.

Granice prywatności i claimy
Nie wolno obiecywać anonimowości. PSP, blockchain, bank albo reseller mogą posiadać własne dane i obowiązki prawne.

Test akceptacyjny
Przejsć cały flow w Playwright: wybór tieru, płatność sandbox albo symulowana, emisja tokenu, claim, paczka, bootstrap event i wpis WORM audit.

Perspektywa portalu: B2B company

Cel biznesowy
Firma kupuje subskrypcję, chce fakturę, VAT, dane nabywcy, możliwość wielu tokenów i rozliczalność.

Funkcjonalność wymagana w UI
Wybór tieru, dane firmy, checkout/invoice, tokeny dla operatorów, panel rozliczeniowy albo eksport faktur.

Obsługa i odzyskanie
Odzyskanie przez firmowy proces finansowy i uprawnionego reprezentanta, nie przez prywatny seed operatora.

Granice prywatności i claimy
B2B ma więcej danych osobowych/firmowych i dłuższą retencję księgową. Prywatność jest mniejsza niż w ścieżce crypto/private.

Test akceptacyjny
Przejsć cały flow w Playwright: wybór tieru, płatność sandbox albo symulowana, emisja tokenu, claim, paczka, bootstrap event i wpis WORM audit.

Perspektywa portalu: Reseller

Cel biznesowy

Partner kupuje pule tokenów z rabatem, może sprzedawać skonfigurowany Pixel/Puli AX i przekazać paczki startowe.

Funkcjonalność wymagana w UI

Reseller console: batch order, rabat 20%, inventory tokenów, status unclaimed/claimed/expired, download paczek tylko dla tokenów przypisanych.

Obsługa i odzyskanie

Reseller nie zna sekretów operatora, FIDO2, HSM ani recovery seed klienta. Może mieć tylko dane handlowe i sprzętowe.

Granice prywatności i claimy

Wymaga umowy, KYC/KYB resellera, limitów, audytu i możliwości odcięcia puli tokenów przy nadużyciu.

Test akceptacyjny

Przejszć cały flow w Playwright: wybór tieru, płatność sandbox albo symulowana, emisja tokenu, claim, paczka, bootstrap event i wpis WORM audit.

Perspektywa portalu: Admin / finance

Cel biznesowy

Zespół wewnętrzny rozlicza płatności, webhooki, tokeny, resellerów, faktury i spójność z provisioningiem.

Funkcjonalność wymagana w UI

Monitoring płatności, reconciliation, ręczne oznaczenie sporu, revoke unclaimed token, retry webhook, export księgowy.

Obsługa i odzyskanie

Admin nie widzi pełnych danych kart, seedów, prywatnych kluczy ani sekretów operatora.

Granice prywatności i claimy

Każda ręczna ingerencja w token albo płatność wymaga WORM audit i powiązania z payment event.

Test akceptacyjny

Przejszć cały flow w Playwright: wybór tieru, płatność sandbox albo symulowana, emisja tokenu, claim, paczka, bootstrap event i wpis WORM audit.

X12. Szczegółowe adaptery płatności

Adapter płatności nie może samodzielnie tworzyć operatora. Jego jedynym skutkiem jest zweryfikowany payment event, który po przejściu ledger lock pozwala wyemitować token. Token claim dopiero uruchamia provisioning.

Adapter płatności: Stripe

Rola w platformie

Główna bramka kart, walletów i metod lokalnych; używać Stripe Checkout/Payment Element i oficjalnych webhooków.

Zakres metod

Karty, portfele i lokalne metody zależne od kraju, waluty i konfiguracji konta. Stablecoin/crypto tylko jeśli dostępne po onboarding i prawnie zatwierdzone.

Wymagane kontrole

Webhook signature verification, idempotency key, fetch payment/session from Stripe API before token mint.

Uwagi prawnoprywatnościowe

Nie przechowywać danych kart w SYLION. PCI scope ma pozostać po stronie Stripe-hosted UI.

Failure modes

Provider timeout, webhook duplicate, status mismatch, chargeback/refund request, manual dispute, underpayment albo expired checkout. Każdy przypadek musi mieć deterministyczny stan order i brak nieautoryzowanej emisji tokenu.

Dowody produkcyjne

Log idempotency key, provider event id, verified status fetch, token ledger event, audit actor=system/provider-adapter.

Adapter płatności: CoinGate

Rola w platformie

Primary crypto payment adapter dla BTC/ETH/LN/stablecoin i innych walut obsługiwanych przez providera.

Zakres metod

Crypto checkout/order API, statusy płatności, settlement zgodnie z konfiguracją merchant.

Wymagane kontrole

Callback/webhook verification, paid/confirmed status, exchange-rate lock window, under/overpayment handling.

Uwagi prawno-prywatnościowe

Crypto nie oznacza pełnej anonimowości. Blockchain i provider mogą umożliwiać korelację i compliance review.

Failure modes

Provider timeout, webhook duplicate, status mismatch, chargeback/refund request, manual dispute, underpayment albo expired checkout. Każdy przypadek musi mieć deterministyczny stan order i brak nieautoryzowanej emisji tokenu.

Dowody produkcyjne

Log idempotency key, provider event id, verified status fetch, token ledger event, audit actor=system/provider-adapter.

Adapter płatności: Mollie

Rola w platformie

Backup PSP dla UE i metod lokalnych, szczególnie gdy Stripe jest niedostępny albo wymagana jest metoda lokalna.

Zakres metod

Hosted checkout, karty, przelewy i metody regionalne zależne od kraju i aktywacji.

Wymagane kontrole

Webhook + API status verification, idempotency, payment state machine.

Uwagi prawno-prywatnościowe

Mollie jest fallback, ale nie może generować innego tokenu dla tego samego order bez ledger lock.

Failure modes

Provider timeout, webhook duplicate, status mismatch, chargeback/refund request, manual dispute, underpayment albo expired checkout. Każdy przypadek musi mieć deterministyczny stan order i brak nieautoryzowanej emisji tokenu.

Dowody produkcyjne

Log idempotency key, provider event id, verified status fetch, token ledger event, audit actor=system/provider-adapter.

Adapter płatności: Manual/invoice wire

Rola w platformie

Opcja B2B enterprise, gdy firma wymaga faktury pro-forma, przelewu lub procurement process.

Zakres metod

Token generowany dopiero po ręcznym/księgowym potwierdzeniu płatności albo po zatwierdzonej polityce kredytu.

Wymagane kontrole

Four-eyes dla ręcznego paid override, dokument księgowy, WORM audit.

Uwagi prawno-prywatnościowe

Nie używać dla B2C automatycznego self-service bez procedury antyfraud.

Failure modes

Provider timeout, webhook duplicate, status mismatch, chargeback/refund request, manual dispute, underpayment albo expired checkout. Każdy przypadek musi mieć deterministyczny stan order i brak nieautoryzowanej emisji tokenu.

Dowody produkcyjne

Log idempotency key, provider event id, verified status fetch, token ledger event, audit actor=system/provider-adapter.

X13. Szczegółowe typy tokenów

Token jest kontraktem dostępu do określonej funkcji, nie kontem klienta. Każdy token ma scope, typ, expiry, status, źródło płatności albo źródło resellerskie i niezmienny audit trail.

Token: BOOTSTRAP**Cel**

Pierwsze utworzenie operatora.

Scope i entitlement

tier, okres minimum 12 miesięcy, limity aplikacji, entitlement rotacji, provider policy, hardware package policy.

Reguła użycia

Jednorazowy. Po claimie przechodzi w provisioning_pending/active.

Efekt systemowy

Tworzy operatora, G1/G2, workload plan, paczki Pixel/Puli AX i stan pierwszego logowania.

Wymagany zapis audytowy

token_id, token_type, status transition, actor, claim_id/order_id, entitlement_version, package_manifest_hash jeżeli dotyczy.

Negatywny test

Token po użyciu, po expiry, z błędnym checksum, z błędnym scope albo przypisany do innego resellera musi zostać odrzucony bez ujawniania, który element był poprawny.

Token: RENEWAL**Cel**

Przedłużenie subskrypcji.

Scope i entitlement

operator_id albo recovery identity, okres, cena, data ważności.

Reguła użycia

Jednorazowy, możliwy tylko dla istniejącego operatora.

Efekt systemowy

Wydłuża expiry, nie zmienia tieru ani infrastruktury poza billing state.

Wymagany zapis audytowy

token_id, token_type, status transition, actor, claim_id/order_id, entitlement_version, package_manifest_hash jeżeli dotyczy.

Negatywny test

Token po użyciu, po expiry, z błędnym checksum, z błędnym scope albo przypisany do innego resellera musi zostać odrzucony bez ujawniania, który element był poprawny.

Token: UPGRADE**Cel**

Podniesienie tieru.

Scope i entitlement

old_tier, new_tier, cost delta, nowe limity, wymagane migracje zasobów.

Reguła użycia

Jednorazowy, wymaga symulacji kosztu i capacity przed apply.

Efekt systemowy

Uruchamia zmianę entitlement i opcjonalną migrację workload/puli.

Wymagany zapis audytowy

token_id, token_type, status transition, actor, claim_id/order_id, entitlement_version, package_manifest_hash jeżeli dotyczy.

Negatywny test

Token po użyciu, po expiry, z błędnym checksum, z błędnym scope albo przypisany do innego resellera musi zostać odrzucony bez ujawniania, który element był poprawny.

Token: ADDON_JURISDICTION**Cel**

Dokupienie rotacji, kraju albo capacity.

Scope i entitlement

kraje, częstotliwość, provider allowlist, liczba rotacji lub okres.

Reguła użycia

Zużywalny albo okresowy, zależnie od produktu.

Efekt systemowy

Zwiększa policy rotacji w panelu operatora bez zmiany bazowego tieru.

Wymagany zapis audytowy

token_id, token_type, status transition, actor, claim_id/order_id, entitlement_version, package_manifest_hash jeżeli dotyczy.

Negatywny test

Token po użyciu, po expiry, z błędnym checksum, z błędnym scope albo przypisany do innego resellera musi zostać odrzucony bez ujawniania, który element był poprawny.

Token: ADDON_APP_CAPACITY**Cel**

Dokupienie dodatkowych środowisk aplikacyjnych.

Scope i entitlement

liczba środowisk, app families, tryb desktop/native, okres.

Reguła użycia

Okresowy, powiązany z subskrypcją.

Efekt systemowy

Zwiększa quota w Workload Control.

Wymagany zapis audytowy

token_id, token_type, status transition, actor, claim_id/order_id, entitlement_version, package_manifest_hash jeżeli dotyczy.

Negatywny test

Token po użyciu, po expiry, z błędnym checksum, z błędnym scope albo przypisany do innego resellera musi zostać odrzucony bez ujawniania, który element był poprawny.

Token: RESELLER_BATCH**Cel**

Pula kodów dla resellera.

Scope i entitlement

reseller_id, discount, liczba tokenów, tier allowlist, expiry, hardware bundle flag.

Reguła użycia

Tokeny potomne jednorazowe; batch ma limit i reconciliation.

Efekt systemowy

Reseller wydaje token klientowi lub wiąże token ze skonfigurowanym sprzętem.

Wymagany zapis audytowy

token_id, token_type, status transition, actor, claim_id/order_id, entitlement_version, package_manifest_hash jeżeli dotyczy.

Negatywny test

Token po użyciu, po expiry, z błędnym checksum, z błędnym scope albo przypisany do innego resellera musi zostać odrzucony bez ujawniania, który element był poprawny.

Token: HARDWARE_BUNDLE**Cel**

Token sprzętowy dla Pixela/Puli AX sprzedanego przez resellera.

Scope i entitlement

device_batch_id, package profile, tier allowlist, reseller_id.

Reguła użycia

Jednorazowy, wiąże claim ze sprzętem/paczką.

Efekt systemowy

Pozwala klientowi aktywować profil bez ujawniania sekretów resellerowi.

Wymagany zapis audytowy

token_id, token_type, status transition, actor, claim_id/order_id, entitlement_version, package_manifest_hash jeżeli dotyczy.

Negatywny test

Token po użyciu, po expiry, z błędnym checksum, z błędnym scope albo przypisany do innego resellera musi zostać odrzucony bez ujawniania, który element był poprawny.

Token: SERVICE_RECOVERY**Cel**

Kontrolowane odzyskanie albo support flow.

Scope i entitlement

scope, operator/recovery identity, expiry krótkie, support case.

Reguła użycia

Krótko żyjący, wymaga ręcznej autoryzacji.

Efekt systemowy

Nie może omijać FIDO2/HSM ani panic policy.

Wymagany zapis audytowy

token_id, token_type, status transition, actor, claim_id/order_id, entitlement_version, package_manifest_hash jeżeli dotyczy.

Negatywny test

Token po użyciu, po expiry, z błędnym checksum, z błędnym scope albo przypisany do innego resellera musi zostać odrzucony bez ujawniania, który element był poprawny.

X14. Szczegółowe widoki i wymagania UI

Portal ma być publiczny, czytelny i kompletny. Najważniejszy ekran to nie landing page marketingowy, tylko konfigurator zakupu i redeem token. Użytkownik musi zrozumieć tier, cenę, minimalny okres, konsekwencje prywatności i dalszy bootstrap.

Widok portalu: Landing/pricing**Co użytkownik widzi**

Pierwszy ekran pokazuje ofertę, porównanie tierów, ceny roczne, minimum 12 miesięcy, limity aplikacji, rotację, dedicated rules.

Co użytkownik może zrobić

CTA: Buy private, Buy as company, Reseller portal, Redeem token.

Wymóg projektowy

Zero marketingowych obietnic anonimowości. Jasne residual risks i legal wording.

Helptipy i legal wording

Każda decyzja wpływająca na prywatność, cenę, minimalny okres, brak refundu, crypto traceability, reseller handoff albo PHANTOM verification gate wymaga krótkiego helptipu i linku do pełnego opisu.

Test UI

Desktop i mobile: brak overflow tekstu, czytelne porównanie tierów, dostępne CTA, poprawne error states, brak lokalnych adresów typu 127.0.0.1 w flow produkcyjnym.

Widok portalu: Tier configurator

Co użytkownik widzi

Karty Pilot/Standard/Pro/Phantom/Sovereign, add-ons, liczba środowisk, rotacje, Matrix, hardware bundle.

Co użytkownik może zrobić

Dynamiczny koszt: subskrypcja, dodatki, hardware, szacunkowy koszt utrzymania infrastruktury.

Wymóg projektowy

Phantom/Sovereign mogą wymagać verification gate przed finalną aktywacją.

Helptipy i legal wording

Każda decyzja wpływająca na prywatność, cenę, minimalny okres, brak refundu, crypto traceability, reseller handoff albo PHANTOM verification gate wymaga krótkiego helptipu i linku do pełnego opisu.

Test UI

Desktop i mobile: brak overflow tekstu, czytelne porównanie tierów, dostępne CTA, poprawne error states, brak lokalnych adresów typu 127.0.0.1 w flow produkcyjnym.

Widok portalu: Payment choice

Co użytkownik widzi

Stripe/Mollie dla fiat, CoinGate dla crypto, manual invoice dla B2B.

Co użytkownik może zrobić

Każda metoda pokazuje prywatność, retencję, settlement time, ryzyka i dostępność.

Wymóg projektowy

Nie generować tokenu przed verified paid.

Helptipy i legal wording

Każda decyzja wpływająca na prywatność, cenę, minimalny okres, brak refundu, crypto traceability, reseller handoff albo PHANTOM verification gate wymaga krótkiego helptipu i linku do pełnego opisu.

Test UI

Desktop i mobile: brak overflow tekstu, czytelne porównanie tierów, dostępne CTA, poprawne error states, brak lokalnych adresów typu 127.0.0.1 w flow produkcyjnym.

Widok portalu: Token delivery

Co użytkownik widzi

Po płatności użytkownik widzi token tylko raz, może pobrać zaszyfrowany receipt/package manifest i instrukcję claim.

Co użytkownik może zrobić

Opcja zapisania recovery seed i test zapisu seed przez użytkownika.

Wymóg projektowy

Portal nie odzyska seed ani plaintext tokenu.

Helptipy i legal wording

Każda decyzja wpływająca na prywatność, cenę, minimalny okres, brak refundu, crypto traceability, reseller handoff albo PHANTOM verification gate wymaga krótkiego helptipu i linku do pełnego opisu.

Test UI

Desktop i mobile: brak overflow tekstu, czytelne porównanie tierów, dostępne CTA, poprawne error states, brak lokalnych adresów typu 127.0.0.1 w flow produkcyjnym.

Widok portalu: Redeem/claim token

Co użytkownik widzi

Pole wpisania tokenu, weryfikacja statusu, wybór trybu: mam sprzęt od resellera / pobierz paczki / aktywuj z Pixel.

Co użytkownik może zrobić

Po claim: provisioning status, paczka Pixel, paczka Puli AX, QR/deep link, status G1/G2/workload.

Wymóg projektowy

Nie pokazywać publicznie 127.0.0.1 jako adresu produkcyjnego.

Helptipy i legal wording

Każda decyzja wpływająca na prywatność, cenę, minimalny okres, brak refundu, crypto traceability, reseller handoff albo PHANTOM verification gate wymaga krótkiego helptipu i linku do pełnego opisu.

Test UI

Desktop i mobile: brak overflow tekstu, czytelne porównanie tierów, dostępne CTA, poprawne error states, brak lokalnych adresów typu 127.0.0.1 w flow produkcyjnym.

Widok portalu: Reseller console

Co użytkownik widzi

Login resellera, batch tokenów, rabat, urządzenia, statusy, zwroty nieclaimed, eksport rozliczeń.

Co użytkownik może zrobić

Reseller może widzieć stan handlowy, ale nie może wejść w operator panel klienta.

Wymóg projektowy

Każdy batch ma limit, expiry, audit i możliwość revoke.

Helptipy i legal wording

Każda decyzja wpływająca na prywatność, cenę, minimalny okres, brak refundu, crypto traceability, reseller handoff albo PHANTOM verification gate wymaga krótkiego helptipu i linku do pełnego opisu.

Test UI

Desktop i mobile: brak overflow tekstu, czytelne porównanie tierów, dostępne CTA, poprawne error states, brak lokalnych adresów typu 127.0.0.1 w flow produkcyjnym.

Widok portalu: B2B billing

Co użytkownik widzi

Dane firmy, VAT, faktury, purchase order, wielokrotne tokeny, role finansowe.

Co użytkownik może zrobić

Firma może zarządzać zakupami, ale nie treścią operatorów.

Wymóg projektowy

Retencja księgowa zgodna z jurysdykcją i polityką prywatności.

Helptipy i legal wording

Każda decyzja wpływająca na prywatność, cenę, minimalny okres, brak refundu, crypto traceability, reseller handoff albo PHANTOM verification gate wymaga krótkiego helptipu i linku do pełnego opisu.

Test UI

Desktop i mobile: brak overflow tekstu, czytelne porównanie tierów, dostępne CTA, poprawne error states, brak lokalnych adresów typu 127.0.0.1 w flow produkcyjnym.

ZAŁĄCZNIK Z - Końcowe porównanie i panel administratora

Ten załącznik odpowiada na pytanie, co realnie zmieniło się między Księgą 3.4 FIXED, PHANTOM v3.0 i Księgą 4.0. Jest umieszczony na końcu dokumentu jako tabela kontrolna dla developerów, architektów, SOC i osób odbierających system.

Z1. Księga 3.4 FIXED vs PHANTOM v3.0 vs Księga 4.0

Obszar	Księga 3.4 FIXED	PHANTOM v3.0	Decyzja Księgi 4.0	Gate/test
Charakter dokumentu	Baseline systemowy, wymagania certyfikowalne, architektura stref i kontroli.	Profil wysokiego ryzyka i moduły autonomiczne [A], wymagające osobnej akceptacji.	Księga 4.0 scala traceability 3.4 z profilem PHANTOM, ale rozdziela baseline od [A].	HUMAN GATE dla każdej funkcji PHANTOM, która zmienia baseline.
Zakres produktu	Bezpieczna platforma komunikacyjna, thin client, Matrix, CDR, G1/G2, HSM/PKI.	Hardening operatora, rotacja, mocniejsza izolacja, profil pracy w środowisku podwyższonego ryzyka.	Panel, portal i operator działają jako produkt; PHANTOM pozostaje profilem kontrolowanym.	Zakaz mieszania claimów PHANTOM z certyfikowalnym core.
Terminal	Thin client bez danych operacyjnych na urządzeniu końcowym.	Pixel/GrapheneOS jako terminal o podwyższonych wymaganiach admission.	Pixel i laptop są terminalami operatora; dane i aplikacje pozostają w workloadach.	Test: storage check, ADB human regression, session expiry.
Router	Router dostępowy jako element ścieżki, bez zaufania do danych aplikacyjnych.	Puli AX/validated equivalent jako element admission i policy, z osobnym profilem hardening.	Puli AX jest aktualnym kandydatem wdrożeniowym, dopóki przejdzie kwalifikację sprzętową.	Test: kill switch, DNS leak, restart recovery, route evidence.
G1/G2	Rozdział gateway i brokera dostępu. Brak bypassu wokół G1/G2.	Ścieżka zastrzona, broker docelowo ślepy wobec treści streamu.	Każdy operator dostaje indywidualne G1 i G2; workload może być współdzielony lub dedykowany wg tieru.	Test: negative route, session cap, no stream persistence.
Workload	Izolacja środowisk aplikacji, CDR na granicy plików, minimalizacja lateral movement.	Silniejsza izolacja Firecracker/bare metal/confidential computing w wyższych tierach.	Pilot/Standard mogą korzystać z pul współdzielonych, Pro+ z Firecracker, Phantom/Sovereign z dedykacją wg policy.	Test: recreate proof, VM/container ID change, app usability.
Aplikacje	Autoryzowane aplikacje i kontrola dostępu przez panel.	Wersje desktop/native oceniane pod kątem izolacji i realnego użycia.	Globalny katalog aplikacji dodaje tylko superadmin; operator wybiera liczbę instancji w ramach tieru.	Test: launcher, stream, input, account-state, limitations explicit.
CDR	Kontrola transferu plików jako obowiązkowa granica bezpieczeństwa.	CDR pozostaje wymagany, bo PHANTOM nie może polegać na zaufaniu do plików przychodzących.	CDR jest obowiązkowy u każdego operatora, raportowany w admin/SOC jako metadane i decyzje.	Test: malicious corpus, quarantine, hash, allow/deny.
HSM/FIDO2	HSM/PKI i FIDO2 jako elementy docelowego zaufania i step-up.	FIDO2 staje się krytycznym elementem admission profilu PHANTOM.	UI i modele konfiguracji są wymagane teraz; fizyczne testy HSM/FIDO2 są gate końcowy.	Test: placeholder state, policy deny, later hardware acceptance.
Rotacja jurysdykcyjna	Rotacja jako polityka infrastruktury i dostępności providerów.	Silniejsza rotacja w profilu wysokiego ryzyka, z akceptacją ryzyka metadanych.	Niższe tiery mogą być przenoszone między istniejącymi zasobami; wyższe mogą dostawać nowe/dedykowane zasoby. Po zwolnieniu zasób wraca do puli dopiero po sanityzacji.	Test: entitlement allow/deny, provider capacity, cleanup proof.
Portal zakupowy	Poza zakresem starego baseline albo opisany mniej szczegółowo.	Nie jest core PHANTOM, ale wpływa na bootstrap operatora.	Oddzielny publiczny portal obsługuje płatności, tokeny, resellerów i paczki startowe.	Test: signed webhook, token hash, one-time claim, no admin route exposure.
Panel administratora	Control plane i zarządzanie operatorami/providerami.	Governance, gates, policy i alerty dla funkcji podwyższonego ryzyka.	Admin panel 4.0 jest główną konsolą zarządzania, kosztów, providerów, observability, CDR i incident response.	Test: RBAC, step-up, audit, synthetic anomaly, cost math.
Panel operatora	Sesja, aplikacje i ustawienia bezpieczeństwa operatora.	Kontrola środowisk, TTL, panic policy, rotacja w ramach entitlement.	Operator panel zarządza własnymi workloadami, sesją, backupem, panic levels, Matrix addon i wyborem wersji aplikacji.	Test: Pixel/laptop human regression, app switching, reset/recreate.
Monitoring i blue team	Audit, metadane, alarmy, SRE/SOC.	Wzmocnione wykrywanie anomalii i runtime monitoring.	Panel admina obserwuje ścieżkę Pixel/Puli/G1/G2/workload jako metadane, nie treść wiadomości ani streamu.	Test: alert P0-P3, no content capture, incident workflow.
RF/telecom	Ryzyka telekom i sprzętu opisane jako threat model.	PHANTOM ma ostrzejsze wymagania, ale obszary regulowane są lab-only/governance.	Księga 4.0 opisuje granice i ryzyka, bez instrukcji manipulacji publicznymi identyfikatorami.	HUMAN GATE: counsel/CISO/lab owner.
Status produkcyjny	Baseline wymaga testów, dowodów i release gates.	PHANTOM wymaga osobnego zatwierdzenia i nie jest domyślnym produktem.	Księga 4.0 jest baseline dokumentacyjnym; funkcja działa dopiero po dowodach E5-E7 i gate.	Nie wolno oznaczać funkcji jako works bez realnego testu.

Z2. Panel administratora - mapa informacyjna

Z1. Panel administratora - zarządzanie, provisioning, obserwacja



Panel administratora jest konsolą zarządzania systemem, nie aplikacją do pracy operatora. Ma dawać kontrolę nad operatorami, providerami, subskrypcjami, provisioningiem, monitoringiem, CDR, incident response i kosztami. Jego podstawową zasadą jest: widzieć stan i metadane, ale nie widzieć treści pracy operatora.

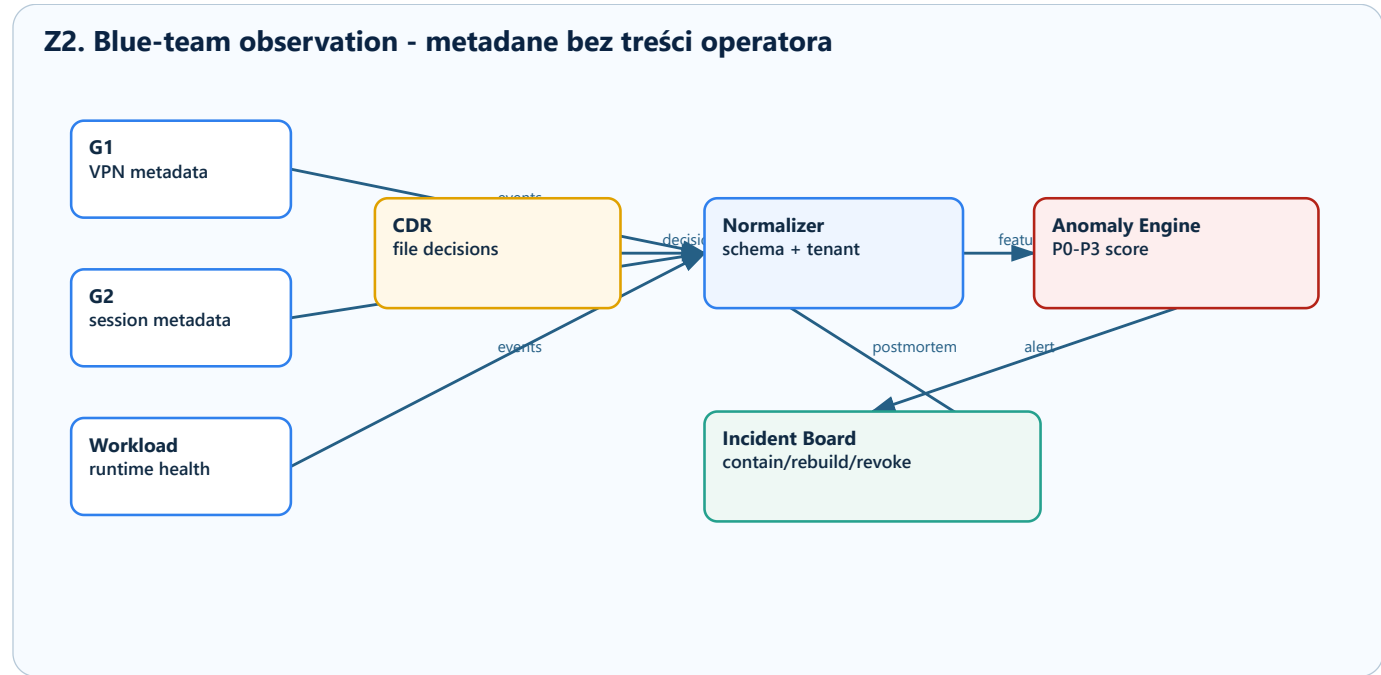
Zakładka	Co pokazuje	Akcje	Czego nie pokazuje	Test odbiorczy
Dashboard	Globalny stan systemu, liczba operatorów, tier mix, koszty, alerty, gates, capacity.	Drill-down do operatora, alertu, providera, kolejki provisioningu.	Treść wiadomości, seed, hasła, tokeny providerów.	Playwright dashboard + API health.
Operators	Tabela operatorów: status, tier, koszt miesięczny, expiry, G1/G2/workload, terminale, sesje.	Create from token, suspend, extend, upgrade, rotate, revoke cert, view evidence.	Treść aplikacji i prywatne dane operatora.	CRUD + RBAC + audit event.
Operator Detail	Timeline sesji, app environments, workload IDs, CDR decisions, path status, cost allocation.	Prepare/recreate environment, force reauth, issue package, mark incident.	Sekrety i aktywne hasła.	Human regression na jednym operatorze testowym.
Providers	Hetzner/OVH/inny provider, kraje, API status, ceny, limity, capabilities.	Add provider, rotate credentials, enable/disable region, qualify KVM/Firecracker/TDX/SEV-SNP.	Plaintext API sekret po zapisaniu.	Provider capability matrix + secret redaction.
Subscriptions/Tiers	Pilot/Standard/Pro/Phantom/Sovereign, ceny, minima, limity aplikacji, rotacja, dedicated rules.	Edit policy, publish version, simulate entitlement.	Ręczna zmiana bez wersjonowania.	Quota enforcement tests.
Tokens/Billing/Resellers	Token ledger, payment provider, reseller pool, rabaty, invoice/company metadata.	Generate token, revoke unclaimed, assign reseller, reconcile webhook.	Pełne dane karty, prywatne dane portfeli.	Webhook signature + idempotency.
Apps Catalog	Autoryzowane aplikacje, tryby desktop/web/native, wersje, wymagane konta, ograniczenia.	Add global app, disable app, pin version, mark limited/works/broken.	Operator nie może dodawać global app.	App launch and state test.
Workloads	Pool bare metal, Firecracker/container inventory, per-operator allocation, health, recreate state.	Allocate, recreate, quarantine host, drain host, move operator.	Cross-tenant file or process visibility.	Isolation and recreate proof.
Provisioning	Kolejka tworzenia G1, G2, workload, Pixel package, router package.	Retry failed step, cancel, resume, inspect safe logs.	Provider secret, SSH private key material.	End-to-end operator bootstrap dry run.
Terminal/Devices	Pixel/laptop/router inventory, CA state, cert serials, posture, last seen.	Revoke device, issue package, require re-enroll.	Local terminal contents.	Device admission negative tests.
PKI/HSM/FIDO2	CA hierarchy, cert issuance, HSM/FIDO2 placeholders, hardware readiness.	Configure policy, require step-up, later enroll hardware.	Private keys.	Policy state and future hardware gate.
CDR	File policy, quarantine, allow/deny, hashes, transformations, unsupported formats.	Change policy, release/quarantine with approval, export evidence.	File content preview unless policy-approved analysis sandbox.	Malicious corpus tests.
Monitoring/SOC	Path health, tunnel flaps, auth failures, key changes, provider errors, anomaly score.	Acknowledge alert, create incident, isolate component, request rebuild.	Message content or pixel stream capture.	Synthetic alert P0-P3.
Incident Response	Incident board, severity, owners, containment actions, evidence chain.	Contain, revoke, rotate, rebuild, close with postmortem.	Destructive action without gate.	IR tabletop + dry-run.
Audit/WORM	Immutable audit events, admin actions, policy versions, token claims, provider calls.	Search, export evidence, verify tamper proof.	Editable audit history.	Tamper negative test.
PHANTOM Governance	Human gates, lab-only records, residual risks, exception register.	Open/close gate, attach approval, block execution.	Operational restricted SOP in product UI.	Gate must block unsafe execution.
Release Gates	Production readiness by module, test evidence E0-E8, known blockers.	Promote/demote feature state.	Works label without E5/E6 evidence.	Release checklist audit.

Z3. Zarządzanie - główne workflow administratora

Workflow	Przebieg	Reguły bezpieczeństwa	Dowody
Create operator from token	Portal token claimed -> admin verifies tier -> provisioning plan -> G1/G2/workload -> Pixel/Puli packages -> operator first login.	Admin can retry failed step; cannot bypass entitlement.	token hash, plan ID, provision IDs, package hashes, audit event.
Provider onboarding	Add provider metadata -> add secret via vault path -> qualify countries/capabilities -> run test provision -> mark region available.	Secret never re-displayed; destructive changes require step-up.	capability report, API health, cost template.
Tier change	Select operator -> simulate new cost/quota -> approve -> apply subscription policy version -> update quotas and rotation rights.	Downgrade cannot orphan running environments silently.	old/new policy, cost delta, quota result.
Jurisdiction rotation	Operator request or schedule -> entitlement check -> provider capacity -> allocate target -> migrate/recreate -> verify path -> release old resource after cleanup.	Lower tier can reuse sanitized pool; higher tier may require new/dedicated resources.	route evidence, cleanup proof, allocation event.
Workload recreate	Operator clicks prepare new session or admin forces rebuild -> stop old env -> cleanup -> start new env -> verify stream/input.	Must change runtime ID and fail if stream is not usable.	old/new IDs, health check, human test state.
Authorized app lifecycle	Superadmin adds app -> security review -> version pin -> workload image update -> operator entitlement -> launch tests.	Operator may create own instances only within approved app and quota.	app manifest, version, test evidence.
Incident containment	Alert -> severity -> owner -> containment action -> evidence preservation -> rebuild/revoke -> postmortem.	No panic/full destroy without pre-approved legal policy.	incident ID, timestamps, approvals, actions.
Device revoke	Lost Pixel/laptop/router -> revoke cert -> invalidate sessions -> require package regeneration -> verify old device denied.	Current session must end at once.	cert serial, deny test, new package hash.

Z4. Obserwacja i analiza blue-team

Z2. Blue-team observation - metadane bez treści operatora



Obszar obserwacji	Co mierzymy	Co analizujemy	Zakaz
Path map	Pixel/Puli AX/G1/G2/workload status, tunnel up/down, latency bands, last seen.	Route break, direct bypass attempt, unexpected path change.	No payload, no message content, no pixel recording.
Cost and capacity	Per-operator monthly cost, bare-metal pool share, G1/G2 VPS cost, transfer, storage.	Cost spike, over-quota app count, underutilized host.	No payment card secrets.
Session security	Session TTL, unlock state, failed reauth, device posture.	Repeated failed unlock, expired session still active, device mismatch.	No passwords/FIDO private material.
Provider health	API status, rate limits, provision failures, region capacity.	Provider outage, credential failure, region depletion.	No secret value display.
CDR telemetry	File type, hash, allow/deny/quarantine, transform result.	Quarantine spike, unknown format, suspicious source.	No file preview by default.
Workload health	Runtime state, CPU/RAM, stream reachable, app state works/limited/broken.	Crash loop, black screen, input failure, recreate failure.	No app content logs.
Anomaly scoring	Weighted score from auth, route, key, CDR, provider, runtime and cost signals.	P0-P3 alert, incident creation, forced reauth.	Score explanations are metadata only.
Audit analytics	Admin action sequence, policy version changes, approval chain.	Four-eyes bypass attempt, unusual admin pattern.	No mutable audit records.

Z5. Uprawnienia, widoczność i testy panelu admina

Moduł	Admin widzi	Admin może	Admin nie widzi/nie może	Test
Operatorzy	tier, expiry, status, G1/G2/workload, cost, last session, risk	create/suspend/upgrade/rotate/revoke	content, passwords, seeds	table filters + RBAC
Providerzy	countries, capabilities, prices, health, capacity	add/edit/disable/qualify	secret after save	secret redaction + region test
Subskrypcje	price, minimum term, quota, rotation rights, dedicated rules	version policy, simulate impact	unversioned manual mutation	entitlement tests
Monitoring	metadata, alert score, path health, incident status	ack/isolate/rebuild/revoke	payload and stream content	synthetic anomaly
CDR	decision, hash, file type, transform, quarantine	release/quarantine/change policy	file content by default	malicious corpus
PHANTOM	gates, approvals, residual risks, lab-only records	open/close gate, block unsafe feature	restricted operational SOP	gate deny test

Z6. KPI/SLO i kryteria uznania funkcji za działającą

Kryterium	Cel	Źródło dowodu	Alert
Admin dashboard load	p95 < 2.5s	browser synthetic	P2 if exceeded 3 consecutive runs
Operator create plan	< 30s to plan, provisioning async	API timing	P1 if token claim blocked
G1/G2 tunnel uptime	>= 99.5% pilot, higher tiers by SLA	metadata probes	P1 if active operator affected
Workload recreate	< 5 min container, < 15 min Firecracker target after image cached	runtime event timestamps	P1 if failed twice
Stream usability	visible image + input + scroll + app switch	ADB/laptop human regression	P0 for active production app unusable
CDR queue	p95 < 60s for supported files	queue metrics	P2 if delay without operator impact
Alert MTTD	< 60s for P0/P1 synthetic signals	SIEM test	P1 if missed
Audit write	100% admin actions produce WORM event	audit test	P0 if missing destructive action event

Z7. Zasady akceptacji

- Funkcja nie może mieć statusu works, jeżeli nie ma dowodu E5 lub E6 tam, gdzie wymagany jest realny test człowieka albo test granicy bezpieczeństwa.
- Panel admina nie może przechowywać ani wyświetlać sekretów po zapisie. Każdy sekret ma być oznaczony jako configured/not configured, z fingerprintem lub identyfikatorem bez wartości.

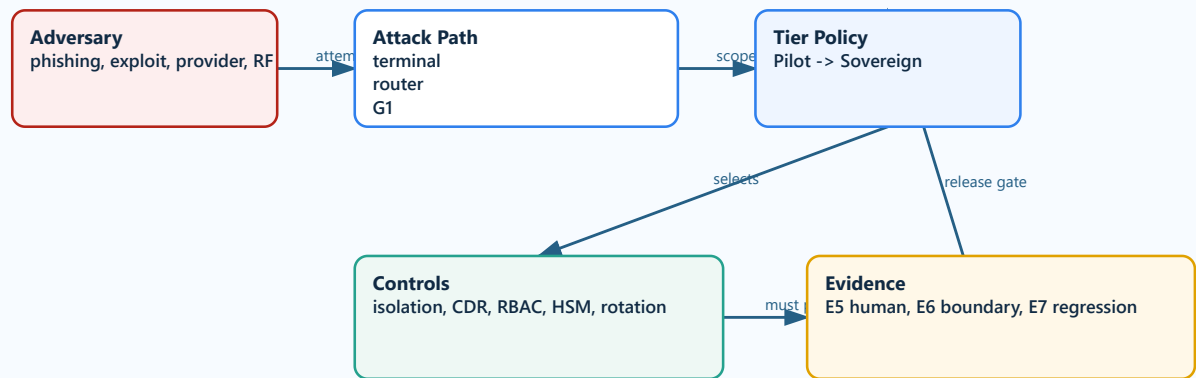
- Monitoring nie może rejestrować treści wiadomości, seedów walletów, haseł, kodów SMS, kluczy prywatnych ani prywatnej zawartości plików operatora.
- Operacje destrukcyjne, panic policy, provider secret rotation, PHANTOM gate i działania IR wymagają niezmiennego wpisu audytowego.
- Obszary regulowane PHANTOM/RF/telecom pozostają w Księdze jako threat model, governance, lab-only i human gate; nie są instrukcją operacyjną ani domyślną funkcją produktu.

ZAŁĄCZNIK Y - Scenariusze ataków i obrona per tier

Ten aneks opisuje scenariusze ataków w stylu analizy zagrożeń: ścieżka ataku, kontrola obronna, różnica między tierami, ryzyko rezydualne i dowód wymagany do uznania kontroli za działającą. Sovereign ma najszerszą ochronę, ale nie jest opisany jako absolutna anonimowość, niewykrywalność ani brak ryzyka.

Y1. Threat scenarios resolved by tier, controls and evidence

Y1. Threat scenarios resolved by tier, controls and evidence



Y1. Postura bezpieczeństwa tierów

Tier	Główna postawa obronna	Przed czym broni najlepiej	Ryzyka rezydualne	Wniosek
Pilot	Podstawowa izolacja operatora, indywidualne G1/G2, mała liczba środowisk aplikacyjnych.	Ataki masowe, typowe malware plikowe przez CDR, podstawowe przejście sesji, błąd operatora.	Współdzielona pula workloadów, mniejsza rotacja, większa ekspozycja na metadane i awarie providerów.	Ma być bezpieczny funkcjonalnie, ale nie jest profilem dla przeciwnika państwowego.
Standard	Więcej środowisk aplikacyjnych, lepsze entitlement, bardziej kompletne monitoring/CDR.	Większość błędów operacyjnych, nadużycia tokenów, typowe próby lateral movement.	Nadal może korzystać ze współdzielonych zasobów workload; rotacja głównie po istniejących pulach.	Dobry poziom dla normalnych operatorów; nie obiecuje pełnej odporności na globalną korelację.
Pro	Firecracker jako cel dla środowisk wysokiego ryzyka, większe limity aplikacji, mocniejsza rotacja.	Eksploity aplikacji, ucieczka z kontenera ograniczana przez microVM, częstsza przebudowa środowisk.	Ryzyko hosta workload i providera nadal istnieje; wymaga dowodów izolacji i recreate.	Pierwszy tier, w którym ochrona workloadu powinna być traktowana jako istotna granica bezpieczeństwa.
Phantom	Profil [A]: silniejsze admission terminal/router/FIDO2, dedykacja wybranych zasobów, PHANTOM gates.	Targeted compromise, silniejsza analiza metadanych, broker/session compromise, supply-chain risk.	Nie jest certyfikowalnym core; wymaga human gate, legal review i jawnego residual-risk acceptance.	Broni szerzej niż Pro, ale nie wolno opisywać go jako pełnej anonimowości albo gwarancji niewykrywalności.
Sovereign	Najszerszy profil: najwyższa dedykacja, własne lub kwalifikowane zasoby, BYO-HSM/KMS, mocne gates.	Ataki providera, insider, supply chain, zaawansowana korelacja, presja prawna i awarie jurysdykcyjne.	Nie usuwa ryzyka RF, fizycznego, błędu człowieka ani globalnej korelacji. Zmniejsza blast radius i zależność od współdzielonej infrastruktury.	Najmocniejszy tier; nadal wymaga operacyjnej dyscypliny, testów E5-E7 i akceptacji ryzyka.

Y2. Głębokość kontroli per tier

Kontrola	Pilot	Standard	Pro	Phantom	Sovereign
Terminal no-data	Tak	Tak	Tak	Tak + admission	Tak + najostrzejsze admission
Indywidualne G1/G2	Tak	Tak	Tak	Tak	Tak
CDR obowiązkowy	Tak	Tak	Tak	Tak	Tak
Workload pool	Współdzielony	Współdzielony	Firecracker preferowany	Częściowo dedykowany	Dedykowany/kwalifikowany
Jurisdiction rotation	Ograniczona/pool	Pool + policy	Częstsza/policy	Zaawansowana/human gate	Najszersza/dedykowane zasoby
HSM/FIDO2	Opcjonalne/roadmap	Opcjonalne/roadmap	Wymuszane dla akcji krytycznych	Element admission	Wymagane w docelowym profilu
Provider risk	Akceptowany	Redukowany	Redukowany przez izolację	Redukowany przez dedykację	Najmocniej redukowany przez BYO-HSM/KMS i perimeter
Blue-team visibility	Podstawowa	Rozszerzona	Pełna metadata observability	Pełna + gates	Pełna + governance + evidence chain
Residual risk wording	Średnie/wysokie	Średnie	Średnie dla hosta/providera	Wysokie scenariusze wymagają akceptacji	Nadal istnieje: RF, fizyczne, globalna korelacja, człowiek

Y3. Scenariusze ataków, obrona i testy

Scenariusz	Ścieżka ataku	Pilot/Standard	Pro	Phantom/Sovereign	Ryzyko rezydualne	Dowód/test
Kradzież albo przejęcie terminala	Atakujący uzyskuje fizyczny dostęp do Pixela/laptopa albo aktywną sesję przeglądarki.	Session TTL brak danych aplikacyjnych lokalnie, cert revoke, forced reauth.	To samo plus krótsze TTL, mocniejsze device posture, opcjonalne wymuszenie FIDO2.	PHANTOM admission: terminal/router/FIDO2 muszą spełnić policy; Sovereign wymaga najściślejszego revoke i evidence.	Aktywna odblokowana sesja może ujawnić aktualny widok do czasu wygaszenia/reakcji.	ADB/laptop test: revoke device -> stara sesja traci dostęp.

Podłożona sieć Wi-Fi / rogue access path	Atakujący próbuje skierować terminal poza oczekiwaną ścieżkę albo przez fałszywy punkt dostępu.	Terminal używa dopuszczzonego profilu, VPN do G1, route negative tests.	Dodatkowe posture checks i alerty direct-bypass.	Phantom/Sovereign wymagają silniejszego powiązania terminal-router-policy i blokady sesji przy naruszeniu ścieżki.	Ryzyko RF i konfiguracji użytkownika pozostaje; nie wszystko da się zweryfikować wyłącznie oprogramem.	Test: Pixel/Puli -> G1/G2 only, direct route denied, DNS leak denied.
Kompromitacja routera dostępowego	Router zostaje przejęty albo błędnie skonfigurowany, próbuje podsłuchu, DNS leak albo bypass.	Kill switch, DNS leak prevention, tunel do G1, brak danych aplikacyjnych w routerze.	Więcej telemetriki, alerty tunnel flap i route mismatch.	Phantom/Sovereign nie ufają routerowi jako miejscu przechowywania danych; router jest elementem admission, nie właścicielem sekretów workloadu.	Baseband/firmware routera i WAN metadata pozostają ryzykiem.	Test: restart routera, brak tunelu = brak internetu dla ścieżki operatora.
Kompromitacja G1	Atakujący próbuje pivotować z gateway do G2 albo zdobyć dane operatora.	G1 indywidualne per operator, brak danych aplikacyjnych, minimal services, rebuild/revoke.	Szybsze rebuildy i alerty metadanych.	Phantom/Sovereign preferują ostrzejszą izolację, krótsze życie certów i mocniejszy incident workflow.	G1 nadal widzi metadane tunelu i może być punktem DoS.	Test: G1 compromised drill -> revoke cert, rebuild, direct app data absent.
Kompromitacja G2 / brokera sesji	Atakujący uzyskuje dostęp do brokera streamingu i próbuje podejrzeć lub przejąć aktywną sesję.	Session caps, no persistence, RBAC, monitoring, storage/log check.	Preferencja Firecracker/workload isolation i twardsze limity sesji.	Phantom/Sovereign docelowo wymagają blind broker/E2EE stream; jeśli broker widzi stream, status musi być residual high.	Aktywna sesja może być ryzykiem do czasu wdrożenia blind-broker target.	Test: no stream persistence + session cap + broker compromise tabletop.
Exploit aplikacji komunikatora	Błąd w Signal/Telegram/WhatsApp/Threema/Zangi/DuckDuckGo/LibreOffice/Exodus daje kod w środowisku aplikacji.	Izolowane środowisko, recreate, CDR dla plików, brak lokalnych danych terminala.	Pro używa Firecracker jako oczekiwanej granicy ryzyka dla bardziej wrażliwych środowisk.	Phantom/Sovereign wymagają najściślej izolacji, pinowania wersji, evidence app-state i szybkiego rebuild.	Jeśli exploit ucieknie z VM/hosta, potrzebny jest incident response i host quarantine.	Test: app crash/recreate, old runtime ID != new runtime ID, no cross-app visibility.
VM/container escape z workloadu	Atakujący wychodzi z kontenera albo microVM na hosta i próbuje dostać się do innych operatorów.	Pilot/Standard: ograniczenia kontenera i network policy; residual risk wyższy.	Pro: Firecracker jako wymagana redukcja ryzyka dla bardziej wrażliwych środowisk.	Phantom/Sovereign: dedykacja hosta lub mocniejsze hardware isolation, monitoring runtime, host quarantine.	Żadna warstwa nie eliminuje całkowicie ryzyka 0-day w VMM/kernel.	Test: lab-only escape simulation, runtime syscall alert, tenant isolation negative test.
Złośliwy plik albo załącznik	Plik z makrem, exploitem dokumentu, payloadem albo steganografią trafia do operatora.	CDR obowiązkowy, unsupported formats blocked, quarantine, hash.	Tak samo, z mocniejszymi policy i większą obserwacją anomalii.	Phantom/Sovereign wymagają surowszych reguł release z quarantine i lepszego evidence chain.	CDR nie daje absolutnej skuteczności wobec wszystkich formatów i technik evasion.	Test: corpus DOCX/PDF/archive/image, allow/deny/quarantine verified.
Provider snapshot / insider providera	Provider próbuje snapshotu, obserwacji metadanych, manipulacji hostem albo działa pod presją prawną.	Szyfrowanie, minimalny stan, osobne G1/G2 per operator, audit.	Większe tery mają mocniejszą rotację i mniej współdzielony blast radius.	Sovereign ma najszerszy model: dedykowane/kwalifikowane zasoby, BYO-HSM/KMS, możliwość osobnego autonomous perimeter.	Provider nadal widzi część metadanych infrastruktury, a fizyczny atak/supply chain pozostaje residual.	Test: provider capability review, encryption-at-rest evidence, key ownership review.
Przejęcie konta administratora	Atakujący uzyskuje sesję admina i próbuje zmieniać providerów, subskrypcje, operatorów albo policy.	RBAC, step-up, WORM audit, no secret redisplay.	Four-eyes dla operacji destrukcyjnych i provider secret rotation.	Phantom/Sovereign wymagają human gates i explicit risk acceptance dla zmian krytycznych.	Autoryzowany insider nadal może wykonać część działań w swoim zakresie.	Test: permission matrix, step-up negative test, immutable audit for destructive action.
Token/payment/reseller fraud	Fałszywy webhook, replay tokenu, reseller generuje nadmiarowe kody albo próbuje ominąć tier.	Webhook signatures, token hash, one-time claim, idempotency.	Limity resellerów, reconciliation, token scope per tier.	Phantom/Sovereign wymagają dodatkowej weryfikacji przed aktywacją pełnych zasobów.	Ryzyko socjotechniki i płatności poza systemem pozostaje procesowe.	Test: webhook replay, double claim, reseller quota denial.
Nadużycie rotacji jurysdykcyjnej	Operator albo błąd systemu próbuje rotacji poza entitlement, do niedozwolonego kraju albo na nieoczyszczony zasób.	Entitlement deny, provider capability registry, cleanup proof before reuse.	Pro ma częstsze i bardziej elastyczne rotacje; nadal przez policy.	Phantom/Sovereign mogą używać dedykowanych zasobów i wymagają mocniejszego evidence dla migracji.	Rotacja nie ukrywa wszystkich metadanych i nie zastępuje legal review.	Test: deny unauthorized country, sanitize old resource, route evidence.
Matrix federation / własny serwer Matrix	Źle skonfigurowana federacja ujawnia metadane, spamuje albo pozwala na nadużycie serwera.	Matrix addon opcjonalny, policy federation, CDR dla plików.	Większe tery dostają lepszą izolację i monitoring serwera Matrix.	Phantom/Sovereign wymagają osobnej analizy metadanych i legal/compliance review dla konfiguracji sieci.	Metadane federacji i zachowanie użytkowników mogą korelować operatora.	Test: federation policy, abuse scenario, metadata review.
Backup exfiltration albo błędny restore	Atakujący próbuje pobrać backup operatora albo przywrócić go do złego środowiska.	Encrypted backup, ownership binding, audit, no admin content view.	Większe tery: mocniejsze retention i restore gates.	Phantom/Sovereign: silniejszy key ownership, HSM/KMS policy, restoration approval.	Błąd operatora przy eksporcie pozostaje ryzykiem.	Test: restore to wrong operator denied, backup decrypt requires correct owner policy.
DDoS albo awaria dostępności	Atakujący degradowa portal, G1/G2, provider API albo workload pool.	Rate limits, health checks, retry queues, fail-safe session states.	Większe tery: większa separacja capacity i szybszy rebuild.	Sovereign ma najszerszą odporność przez dedykowane zasoby i możliwość alternatywnych providerów/perimeter.	Dostępność nigdy nie jest absolutna; nation-state scale może degradować łączność.	Test: provider outage simulation, queue retry, graceful denial.

Y4. Szczegółowe karty scenariuszy ataku

Tabela Y3 jest szybkim porównaniem. Karty Y4 są wersją operacyjną: każda wskazuje, co musi być widoczne w panelu admina, gdzie kończy się ochrona danego tieru i jaki dowód jest wymagany.

Scenariusz ataku: Kradzież albo przejęcie terminala

Ścieżka ataku

Atakujący uzyskuje fizyczny dostęp do Pixela/laptopa albo aktywną sesję przeglądarki.

Pilot / Standard

Session TTL, brak danych aplikacyjnych lokalnie, cert revoke, forced reauth.

Pro

To samo plus krótsze TTL, mocniejsze device posture, opcjonalne wymuszenie FIDO2.

Phantom / Sovereign

PHANTOM admission: terminal/router/FIDO2 muszą spełnić policy; Sovereign wymaga najściślejszego revoke i evidence.

Ryzyko rezydualne

Aktywna odblokowana sesja może ujawnić aktualny widok do czasu wygaszenia/reakcji.

Dowód i test

ADB/laptop test: revoke device -> stara sesja traci dostęp.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Podłożona sieć Wi-Fi / rogue access path

Ścieżka ataku

Atakujący próbuje skierować terminal poza oczekiwaną ścieżkę albo przez fałszywy punkt dostępu.

Pilot / Standard

Terminal używa dopuszczonego profilu, VPN do G1, route negative tests.

Pro

Dodatkowe posture checks i alerty direct-bypass.

Phantom / Sovereign

Phantom/Sovereign wymagają silniejszego powiązania terminal-router-policy i blokady sesji przy naruszeniu ścieżki.

Ryzyko rezydualne

Ryzyko RF i konfiguracji użytkownika pozostaje; nie wszystko da się zweryfikować wyłącznie softwarem.

Dowód i test

Test: Pixel/Puli -> G1/G2 only, direct route denied, DNS leak denied.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Kompromitacja routera dostępowego

Ścieżka ataku

Router zostaje przejęty albo błędnie skonfigurowany, próbuje podsłuchu, DNS leak albo bypass.

Pilot / Standard

Kill switch, DNS leak prevention, tunel do G1, brak danych aplikacyjnych w routerze.

Pro

Więcej telemetryki, alerty tunnel flap i route mismatch.

Phantom / Sovereign

Phantom/Sovereign nie ufają routerowi jako miejscu przechowywania danych; router jest elementem admission, nie właścicielem sekretów workloadu.

Ryzyko rezydualne

Baseband/firmware routera i WAN metadata pozostają ryzykiem.

Dowód i test

Test: restart routera, brak tunelu = brak internetu dla ścieżki operatora.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Kompromitacja G1

Ścieżka ataku

Atakujący próbuje pivotować z gateway do G2 albo zdobyć dane operatora.

Pilot / Standard

G1 indywidualne per operator, brak danych aplikacyjnych, minimal services, rebuild/revoke.

Pro

Szybsze rebuildy i alerty metadanych.

Phantom / Sovereign

Phantom/Sovereign preferują ostrzejszą izolację, krótsze życie certów i mocniejszy incident workflow.

Ryzyko rezydualne

G1 nadal widzi metadane tunelu i może być punktem DoS.

Dowód i test

Test: G1 compromised drill -> revoke cert, rebuild, direct app data absent.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Kompromitacja G2 / brokera sesji

Ścieżka ataku

Atakujący uzyskuje dostęp do brokera streamingu i próbuje podejrzeć lub przejąć aktywną sesję.

Pilot / Standard

Session caps, no persistence, RBAC, monitoring, storage/log check.

Pro

Preferencja Firecracker/workload isolation i twardsze limity sesji.

Phantom / Sovereign

Phantom/Sovereign docelowo wymagają blind broker/E2EE stream; jeśli broker widzi stream, status musi być residual high.

Ryzyko rezydualne

Aktywna sesja może być ryzykiem do czasu wdrożenia blind-broker target.

Dowód i test

Test: no stream persistence + session cap + broker compromise tabletop.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Exploit aplikacji komunikatora

Ścieżka ataku

Błąd w Signal/Telegram/WhatsApp/Threema/Zangi/DuckDuckGo/LibreOffice/Exodus daje kod w środowisku aplikacji.

Pilot / Standard

Izolowane środowisko, recreate, CDR dla plików, brak lokalnych danych terminala.

Pro

Pro używa Firecracker jako oczekiwanej granicy dla mocniejszych środowisk.

Phantom / Sovereign

Phantom/Sovereign wymagają najściślejszej izolacji, pinowania wersji, evidence app-state i szybkiego rebuild.

Ryzyko rezydualne

Jeśli exploit ucieknie z VM/hosta, potrzebny jest incident response i host quarantine.

Dowód i test

Test: app crash/recreate, old runtime ID != new runtime ID, no cross-app visibility.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: VM/container escape z workloadu

Ścieżka ataku

Atakujący wychodzi z kontenera albo microVM na hosta i próbuje dostać się do innych operatorów.

Pilot / Standard

Pilot/Standard: ograniczenia kontenera i network policy; residual risk wyższy.

Pro

Pro: Firecracker jako wymagana redukcja ryzyka dla bardziej wrażliwych środowisk.

Phantom / Sovereign

Phantom/Sovereign: dedykacja hosta lub mocniejsze hardware isolation, monitoring runtime, host quarantine.

Ryzyko rezydualne

Żadna warstwa nie eliminuje całkowicie ryzyka 0-day w VMM/kernel.

Dowód i test

Test: lab-only escape simulation, runtime syscall alert, tenant isolation negative test.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Złośliwy plik albo załącznik

Ścieżka ataku

Plik z makrem, exploitem dokumentu, payloadem albo steganografią trafia do operatora.

Pilot / Standard

CDR obowiązkowy, unsupported formats blocked, quarantine, hash.

Pro

Tak samo, z mocniejszymi policy i większą obserwacją anomalii.

Phantom / Sovereign

Phantom/Sovereign wymagają surowszych reguł release z quarantine i lepszego evidence chain.

Ryzyko rezydualne

CDR nie daje absolutnej skuteczności wobec wszystkich formatów i technik evasion.

Dowód i test

Test: corpus DOCX/PDF/archive/image, allow/deny/quarantine verified.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Provider snapshot / insider providera

Ścieżka ataku

Provider próbuje snapshotu, obserwacji metadanych, manipulacji hostem albo działa pod presją prawną.

Pilot / Standard

Szyfrowanie, minimalny stan, osobne G1/G2 per operator, audyt.

Pro

Większe tiery mają mocniejszą rotację i mniejszy współdzielony blast radius.

Phantom / Sovereign

Sovereign ma największy model: dedykowane/kwalifikowane zasoby, BYO-HSM/KMS, możliwość osobnego autonomous perimeter.

Ryzyko rezydualne

Provider nadal widzi część metadanych infrastruktury, a fizyczny atak/supply chain pozostaje residual.

Dowód i test

Test: provider capability review, encryption-at-rest evidence, key ownership review.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Przejęcie konta administratora

Ścieżka ataku

Atakujący uzyskuje sesję admina i próbuje zmieniać providerów, subskrypcje, operatorów albo policy.

Pilot / Standard

RBAC, step-up, WORM audit, no secret redisplay.

Pro

Four-eyes dla operacji destrukcyjnych i provider secret rotation.

Phantom / Sovereign

Phantom/Sovereign wymagają human gates i explicit risk acceptance dla zmian krytycznych.

Ryzyko rezydualne

Autoryzowany insider nadal może wykonać część działań w swoim zakresie.

Dowód i test

Test: permission matrix, step-up negative test, immutable audit for destructive action.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Token/payment/reseller fraud

Ścieżka ataku

Fałszywy webhook, replay tokenu, reseller generuje nadmiarowe kody albo próbuje ominąć tier.

Pilot / Standard

Webhook signatures, token hash, one-time claim, idempotency.

Pro

Limity resellerów, reconciliation, token scope per tier.

Phantom / Sovereign

Phantom/Sovereign wymagają dodatkowej weryfikacji przed aktywacją pełnych zasobów.

Ryzyko rezydualne

Ryzyko socjotechniki i płatności poza systemem pozostaje procesowe.

Dowód i test

Test: webhook replay, double claim, reseller quota denial.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Nadużycie rotacji jurysdykcyjnej

Ścieżka ataku

Operator albo błąd systemu próbuje rotacji poza entitlement, do niedozwolonego kraju albo na nieoczyszczony zasób.

Pilot / Standard

Entitlement deny, provider capability registry, cleanup proof before reuse.

Pro

Pro ma częstsze i bardziej elastyczne rotacje; nadal przez policy.

Phantom / Sovereign

Phantom/Sovereign mogą używać dedykowanych zasobów i wymagają mocniejszego evidence dla migracji.

Ryzyko rezydualne

Rotacja nie ukrywa wszystkich metadanych i nie zastępuje legal review.

Dowód i test

Test: deny unauthorized country, sanitize old resource, route evidence.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Matrix federation / własny serwer Matrix

Ścieżka ataku

Źle skonfigurowana federacja ujawnia metadane, spamuje albo pozwala na nadużycie serwera.

Pilot / Standard

Matrix addon opcjonalny, policy federation, CDR dla plików.

Pro

Większe tiery dostają lepszą izolację i monitoring serwera Matrix.

Phantom / Sovereign

Phantom/Sovereign wymagają osobnej analizy metadanych i legal/compliance review dla konfiguracji sieci.

Ryzyko rezydualne

Metadane federacji i zachowanie użytkowników mogą korelować operatora.

Dowód i test

Test: federation policy, abuse scenario, metadata review.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: Backup exfiltration albo błędny restore

Ścieżka ataku

Atakujący próbuje pobrać backup operatora albo przywrócić go do złego środowiska.

Pilot / Standard

Encrypted backup, ownership binding, audit, no admin content view.

Pro

Większe tiery: mocniejsze retention i restore gates.

Phantom / Sovereign

Phantom/Sovereign: silniejszy key ownership, HSM/KMS policy, restoration approval.

Ryzyko rezydualne

Błąd operatora przy eksporcie pozostaje ryzykiem.

Dowód i test

Test: restore to wrong operator denied, backup decrypt requires correct owner policy.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Scenariusz ataku: DDoS albo awaria dostępności

Ścieżka ataku

Atakujący degradowuje portal, G1/G2, provider API albo workload pool.

Pilot / Standard

Rate limits, health checks, retry queues, fail-safe session states.

Pro

Większe tery: większa separacja capacity i szybszy rebuild.

Phantom / Sovereign

Sovereign ma najszerszą odporność przez dedykowane zasoby i możliwość alternatywnych providerów/perimeter.

Ryzyko rezydualne

Dostępność nigdy nie jest absolutna; nation-state scale może degradować łączność.

Dowód i test

Test: provider outage simulation, queue retry, graceful denial.

Wymagany zapis w panelu admina

Alert albo test musi być widoczny w Monitoring/SOC z timestamp, operator_id, affected component, severity, action owner i statusem postmortem. Panel nie pokazuje treści operatora ani sekretów.

Reguła statusu

Dopóki test nie przejdzie na realnej ścieżce albo w kontrolowanym labie, scenariusz pozostaje status=partial/blocked i nie może być opisany jako fully protected.

Y5. Reguła interpretacji

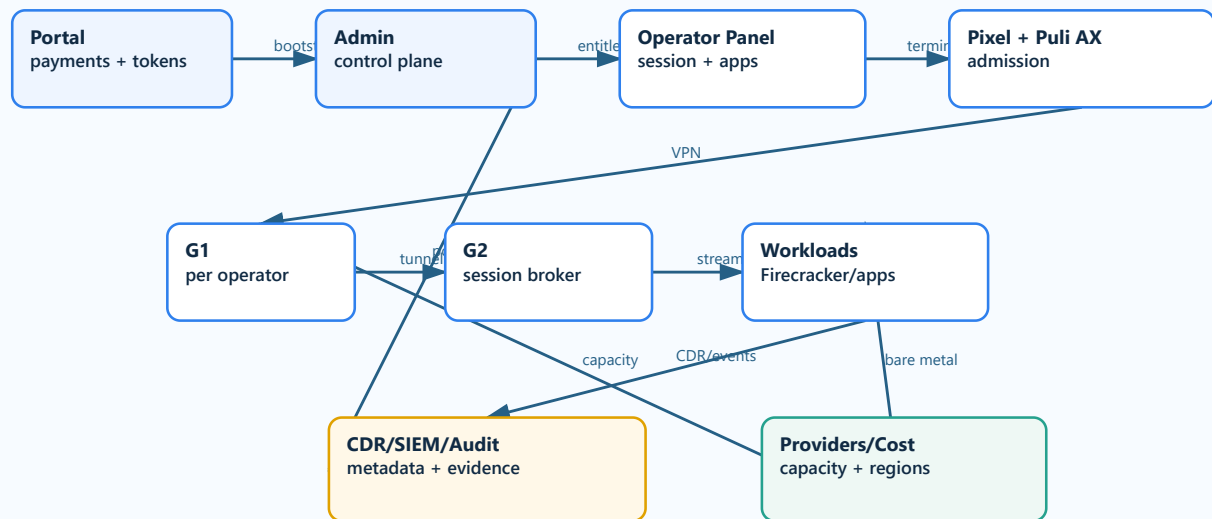
- Pilot i Standard mają chronić przed typowymi błędami, malware, nadużyciami tokenów, podstawowym session abuse i izolować operatorów przez G1/G2 oraz CDR.
- Pro jest pierwszym tierem, w którym Firecracker i silniejsza izolacja workloadu powinny być traktowane jako istotny mechanizm redukcji ryzyka, a nie tylko optymalizacja infrastruktury.
- Phantom jest profilem [A] z dodatkowymi gates, admission i wymaganiami operacyjnymi; nie należy go mieszać z baseline marketingowym.
- Sovereign broni najszerzej, bo minimalizuje współdzielenie zasobów, wzmacnia kontrolę kluczy, ogranicza zależność od providera i wymaga najpełniejszego evidence chain.
- Żaden tier nie usuwa ryzyka aktywnie skompromitowanego terminala, błędu człowieka, fizycznego przejęcia sprzętu, globalnej korelacji metadanych ani supply-chain bez dodatkowego programu kontroli.

Załącznik W - Rozszerzony masterplan modułów, wdrożeń i testów

Ten aneks rozbija SYLION 4.0 na moduły, które mogą być implementowane przez różne zespoły albo modele, ale muszą zostać złożone przez wspólne kontrakty: API, events, audit, ownership, entitlement i test evidence. To jest praktyczna mapa wdrożeniowa, nie skrót marketingowy.

W1. Masterplan modułów i zależności wdrożeniowych

W1. Masterplan modułów i zależności wdrożeniowych



W0. Rejestr modułów

Moduł	Cel	Zależności
Portal Commerce	Publiczny zakup tokenów, konfiguracja tierów, wybór płatności, claim tokenu i wejście do bootstrapu operatora.	Portal, Token Ledger, Payment Adapters, Admin API
Payment Adapters	Wspólna warstwa Stripe, CoinGate, Mollie i manual invoice, bez logiki tworzenia operatora wewnątrz adaptera.	Portal, Token Ledger, Finance, Audit
Token Ledger	Jedno źródło prawdy dla tokenów, claimów, statusów, batchy resellerskich i powiązania z entitlement.	Portal, Admin, Reseller Console, Provisioning
Reseller Console	Obsługa partnerów, batchy tokenów, rabatu, sprzętu, statusów unclaimed/claimed i rozliczeń.	Portal, Token Ledger, Finance, Audit
Admin Dashboard	Główna konsola systemu: operatorzy, koszty, alerty, gates, status providerów i capacity.	Admin API, Monitoring, Providers, Subscriptions
Provider Registry	Rejestr providerów VPS/bare metal, krajów, cen, capabilities, KVM, Firecracker, TDX, SEV-SNP i statusu API.	Admin, Provisioning, Rotation, Cost Engine
Subscription Policy	Wersjonowane polityki tierów, limity środowisk, rotacje, dedykacja zasobów i minimalne okresy subskrypcji.	Portal, Admin, Operator Panel, Provisioning
Operator Registry	Rejestr operatorów, statusów, tierów, kosztów, expiry, device binding, G1/G2/workload i ryzyka.	Admin, Operator Panel, Monitoring, Audit
Operator Panel Shell	Panel pracy operatora: aplikacje, sesja, licznik TTL, Workload Control, settings, backup, panic, Matrix i rotacja.	Operator API, G2, Workloads, Device Admission
Pixel Package	Paczka startowa dla GrapheneOS/Pixel: CA, profile, skróty, browser policy i ścieżka do operator panel.	Portal Claim, Admin Provisioning, Device Inventory
Puli AX Package	Paczka routera: VPN do G1, kill switch, DNS leak prevention, telemetrika health i restart recovery.	Router UI/API, G1, Device Inventory, Monitoring
Device Admission	Warstwa dopuszczająca terminal/router/FIDO2/HSM policy do sesji, bez zaufania do samego urządzenia.	Pixel, Puli AX, G1, PKI, Operator Panel
G1 Gateway	Indywidualny gateway operatora, przyjmujący tylko dopuszczony ruch i nieprzechowujący danych aplikacyjnych.	Puli AX, G2, PKI, Monitoring
G2 Session Broker	Broker sesji i streamingu do workloadu, z limitami połączeń, brakiem persistence i roadmapą blind broker.	G1, Workload Orchestrator, Operator Panel
Streaming/Input Bridge	Warstwa obrazu i wejścia: dopasowanie do Pixela/laptopa, klawiatura, scroll, app switching i powrót do panelu.	G2, Workload Apps, Pixel Browser, Laptop Browser
Workload Orchestrator	Planowanie, uruchamianie, recreate, destroy i status środowisk aplikacyjnych zgodnie z entitlement.	Admin, Operator Panel, Firecracker Host Pool, App Catalog
Firecracker Host Pool	Bare-metal/KVM pool dla microVM, izolacja tenantów, host quarantine, capacity i evidence isolation.	Provider Registry, Workload Orchestrator, Monitoring
Application Catalog	Globalny katalog autoryzowanych aplikacji i trybów: desktop, web, Android-native, limited/works/broken.	Admin, Operator Panel, Workload Images
Application Environments	Instancje komunikatorów i narzędzi: Signal, Telegram, WhatsApp, Threema, Zangi, DuckDuckGo, LibreOffice, Exodus.	Workload Orchestrator, Streaming, CDR, Monitoring
CDR Pipeline	Granica transferu plików: allow/deny/quarantine, hash, transform, unsupported formats i evidence chain.	Operator Panel, Workloads, Admin SOC
Matrix Server Addon	Opcjonalny własny Matrix, polityka federacji, CDR, monitoring metadanych i add-on billing.	Operator Panel, Workloads, Provider Registry
Backup/Panic Policy	Backup operatora, restore, inactivity wipe, panic levels i legal pre-approval dla działań destrukcyjnych.	Operator Panel, Admin, Audit, Storage
Jurisdiction Rotation	Rotacja krajów/providerów według tieru, reuse sanitized pools i dedykacja wyższych tierów.	Subscription Policy, Provider Registry, G1/G2, Workloads
Monitoring/SIEM	Blue-team metadane bez treści: health, route, auth, CDR, provider, cost, workload, anomaly score.	All Components, Admin Dashboard, Incident Response
Anomaly Engine	Ocena P0-P3 z sygnałów routingu, kluczy, CDR, workload, providerów i admin actions.	Monitoring, Admin, Audit, Incident Response
Incident Response	Containment, revoke, rebuild, rotate, quarantine, postmortem i ownery dla każdego alertu.	Admin, Monitoring, G1/G2, Workloads, Audit
Audit/WORM Evidence	Niezmienny zapis tokenów, płatności, admin actions, provisioning, CDR, incidents i release gates.	Portal, Admin, Operator, SRE, SOC
PKI/HSM/FIDO2	CA, certyfikaty, device certs, step-up, HSM/FIDO2 UI i późniejsze hardware acceptance tests.	Admin, Device Admission, G1/G2, Operator Security
Cost Engine	Koszt operatora: G1, G2, workload, bare metal share, transfer, storage, add-ons i provider capacity.	Provider Registry, Subscriptions, Admin Dashboard
Human Regression Lab	Testy jak człowiek przez Pixel/laptop: klik, wpisywanie, scroll, aplikacje, reset, streaming, przełączanie.	Pixel ADB, Playwright, Operator Panel, Workloads
Release Gates	System decyzyjny works/partial/blocked oparty o E0-E8, testy negatywne, dowody i human gate.	All Modules, Admin, Audit

W0.1 Fazy wdrożenia

Faza	Zakres	Warunek przejścia
Faza 1	Portal, token ledger, payment adapters	Signed webhook, one-time token, B2C/B2B/reseller flows.
Faza 2	Admin core i provider registry	Provider capabilities, subscriptions, operator table, audit.
Faza 3	Operator panel i workload control	App launcher, recreate, session TTL, backup/panic UI.
Faza 4	Pixel/Puli/G1/G2 path	Real route evidence, DNS leak prevention, no bypass.
Faza 5	Workload isolation i aplikacje	DuckDuckGo, LibreOffice, communicators, Exodus, app state labels.
Faza 6	CDR, backup, Matrix, rotation	File corpus, Matrix addon, rotation policy, cleanup proof.
Faza 7	SOC, anomalie, IR	P0-P3 alerts, incident workflows, WORM evidence.
Faza 8	HSM/FIDO2/router final hardening	Hardware acceptance, step-up, PHANTOM gates.

W0.2 Hierarchia dowodów release

Poziom	Nazwa	Dowód	Uwagi
E0	Opis wymagań	Sekcja Księgi, ADR, user story	Nie potwierdza działania.
E1	Static review	Review architektury, threat model, legal/compliance wording	Nie potwierdza runtime.
E2	Unit/API contract	Testy funkcji i schematów API	Nie potwierdza integracji.
E3	Integration	Portal->token->admin, operator->workload, CDR flow	Nie potwierdza UX człowieka.
E4	Live metadata probe	Rzeczywisty health path i reachability	Nie potwierdza usability.
E5	Human regression	Pixel/laptop klikany jak człowiek	Warunek dla aplikacji i streamingu.
E6	Negative security	Bypass denied, forged webhook denied, double claim denied	Warunek dla granic bezpieczeństwa.
E7	Repeatable regression	Automatyczny, powtarzalny zestaw testów	Warunek przed release.
E8	Human gate	Akceptacja CISO/legal/owner	Nie zastępuje testów technicznych.

W1. Portal Commerce

Publiczny zakup tokenów, konfiguracja tierów, wybór płatności, claim tokenu i wejście do bootstrapu operatora.

Zakres funkcjonalny

Cel modułu

Publiczny zakup tokenów, konfiguracja tierów, wybór płatności, claim tokenu i wejście do bootstrapu operatora.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Portal, Token Ledger, Payment Adapters, Admin API

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Portal Commerce musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Portal Commerce musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Portal Commerce, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Portal Commerce oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W2. Payment Adapters

Wspólna warstwa Stripe, CoinGate, Mollie i manual invoice, bez logiki tworzenia operatora wewnątrz adaptera.

Zakres funkcjonalny

Cel modułu

Wspólna warstwa Stripe, CoinGate, Mollie i manual invoice, bez logiki tworzenia operatora wewnątrz adaptera.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Portal, Token Ledger, Finance, Audit

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Payment Adapters musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Payment Adapters musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Payment Adapters, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloads albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Payment Adapters oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W3. Token Ledger

Jedno źródło prawdy dla tokenów, claimów, statusów, batchy resellerskich i powiązania z entitlement.

Zakres funkcjonalny

Cel modułu

Jedno źródło prawdy dla tokenów, claimów, statusów, batchy resellerskich i powiązania z entitlement.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Portal, Admin, Reseller Console, Provisioning

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Token Ledger musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Token Ledger musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Token Ledger, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Token Ledger oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W4. Reseller Console

Obsługa partnerów, batchy tokenów, rabatu, sprzętu, statusów unclaimed/claimed i rozliczeń.

Zakres funkcjonalny

Cel modułu

Obsługa partnerów, batchy tokenów, rabatu, sprzętu, statusów unclaimed/claimed i rozliczeń.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Portal, Token Ledger, Finance, Audit

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Reseller Console musi mieć widok listy/statusu, widok szczegółów, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Reseller Console musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Reseller Console, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Reseller Console oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W5. Admin Dashboard

Główna konsola systemu: operatorzy, koszty, alerty, gates, status providerów i capacity.

Zakres funkcjonalny

Cel modułu

Główna konsola systemu: operatorzy, koszty, alerty, gates, status providerów i capacity.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Admin API, Monitoring, Providers, Subscriptions

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Admin Dashboard musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Admin Dashboard musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Admin Dashboard, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Admin Dashboard oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W6. Provider Registry

Rejestr providerów VPS/bare metal, krajów, cen, capabilities, KVM, Firecracker, TDX, SEV-SNP i statusu API.

Zakres funkcjonalny

Cel modułu

Rejestr providerów VPS/bare metal, krajów, cen, capabilities, KVM, Firecracker, TDX, SEV-SNP i statusu API.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Admin, Provisioning, Rotation, Cost Engine

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Provider Registry musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Provider Registry musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Provider Registry, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Provider Registry oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W7. Subscription Policy

Wersjonowane polityki tierów, limity środowisk, rotacje, dedykacja zasobów i minimalne okresy subskrypcji.

Zakres funkcjonalny Cel modułu Wersjonowane polityki tierów, limity środowisk, rotacje, dedykacja zasobów i minimalne okresy subskrypcji. Użytkownik lub system Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate. Główne zależności Portal, Admin, Operator Panel, Provisioning Wyjście modułu Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.
Ekrany, API i dane Ekrany/UI Subscription Policy musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka. API Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id. Model danych Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów. Sekrety Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.
Kontrole bezpieczeństwa RBAC i step-up Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka. Granice danych Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora. Audit Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id. Fail closed Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.
Awaryjne i scenariusze naprawy Typowe awarie Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity. Reakcja systemu Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu. Rollback Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy. Obsługa support Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Subscription Policy musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Subscription Policy, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Subscription Policy oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W8. Operator Registry

Rejestr operatorów, statusów, tierów, kosztów, expiry, device binding, G1/G2/workload i ryzyka.

Zakres funkcjonalny

Cel modułu

Rejestr operatorów, statusów, tierów, kosztów, expiry, device binding, G1/G2/workload i ryzyka.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Admin, Operator Panel, Monitoring, Audit

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Operator Registry musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Operator Registry musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Operator Registry, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Operator Registry oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W9. Operator Panel Shell

Panel pracy operatora: aplikacje, sesja, licznik TTL, Workload Control, settings, backup, panic, Matrix i rotacja.

Zakres funkcjonalny
Cel modułu
Panel pracy operatora: aplikacje, sesja, licznik TTL, Workload Control, settings, backup, panic, Matrix i rotacja.
Użytkownik lub system
Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.
Główne zależności
Operator API, G2, Workloads, Device Admission
Wyjście modułu
Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane
Ekrany/UI
Operator Panel Shell musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.
API
Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.
Model danych
Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.
Sekrety
Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa
RBAC i step-up
Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.
Granice danych
Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.
Audit
Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.
Fail closed
Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy
Typowe awarie
Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.
Reakcja systemu
Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.
Rollback
Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.
Obsługa support
Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Operator Panel Shell musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Operator Panel Shell, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Operator Panel Shell oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W10. Pixel Package

Paczka startowa dla GrapheneOS/Pixel: CA, profile, skróty, browser policy i ścieżka do operator panel.

Zakres funkcjonalny

Cel modułu

Paczka startowa dla GrapheneOS/Pixel: CA, profile, skróty, browser policy i ścieżka do operator panel.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Portal Claim, Admin Provisioning, Device Inventory

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Pixel Package musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Pixel Package musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Pixel Package, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Pixel Package oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Walidacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W11. Puli AX Package

Paczka routera: VPN do G1, kill switch, DNS leak prevention, telemetryka health i restart recovery.

Zakres funkcjonalny

Cel modułu

Paczka routera: VPN do G1, kill switch, DNS leak prevention, telemetryka health i restart recovery.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Router UI/API, G1, Device Inventory, Monitoring

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Puli AX Package musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Puli AX Package musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Puli AX Package, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloads albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Puli AX Package oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W12. Device Admission

Warstwa dopuszczająca terminal/router/FIDO2/HSM policy do sesji, bez zaufania do samego urządzenia.

Zakres funkcjonalny

Cel modułu

Warstwa dopuszczająca terminal/router/FIDO2/HSM policy do sesji, bez zaufania do samego urządzenia.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Pixel, Puli AX, G1, PKI, Operator Panel

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Device Admission musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Device Admission musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Device Admission, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Device Admission oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W13. G1 Gateway

Indywidualny gateway operatora, przyjmujący tylko dopuszczony ruch i nieprzechowujący danych aplikacyjnych.

Zakres funkcjonalny

Cel modułu

Indywidualny gateway operatora, przyjmujący tylko dopuszczony ruch i nieprzechowujący danych aplikacyjnych.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Puli AX, G2, PKI, Monitoring

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

G1 Gateway musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł G1 Gateway musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla G1 Gateway, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu G1 Gateway oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W14. G2 Session Broker

Broker sesji i streamingu do workloadu, z limitami połączeń, brakiem persistence i roadmapą blind broker.

Zakres funkcjonalny

Cel modułu

Broker sesji i streamingu do workloadu, z limitami połączeń, brakiem persistence i roadmapą blind broker.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

G1, Workload Orchestrator, Operator Panel

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

G2 Session Broker musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł G2 Session Broker musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla G2 Session Broker, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu G2 Session Broker oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W15. Streaming/Input Bridge

Warstwa obrazu i wejścia: dopasowanie do Pixela/laptopa, klawiatura, scroll, app switching i powrót do panelu.

Zakres funkcjonalny

Cel modułu

Warstwa obrazu i wejścia: dopasowanie do Pixela/laptopa, klawiatura, scroll, app switching i powrót do panelu.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

G2, Workload Apps, Pixel Browser, Laptop Browser

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Streaming/Input Bridge musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Streaming/Input Bridge musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Streaming/Input Bridge, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Streaming/Input Bridge oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W16. Workload Orchestrator

Planowanie, uruchamianie, recreate, destroy i status środowisk aplikacyjnych zgodnie z entitlement.

Zakres funkcjonalny

Cel modułu

Planowanie, uruchamianie, recreate, destroy i status środowisk aplikacyjnych zgodnie z entitlement.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Admin, Operator Panel, Firecracker Host Pool, App Catalog

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Workload Orchestrator musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrola bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Workload Orchestrator musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Workload Orchestrator, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Workload Orchestrator oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W17. Firecracker Host Pool

Bare-metal/KVM pool dla microVM, izolacja tenantów, host quarantine, capacity i evidence isolation.

Zakres funkcjonalny

Cel modułu

Bare-metal/KVM pool dla microVM, izolacja tenantów, host quarantine, capacity i evidence isolation.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Provider Registry, Workload Orchestrator, Monitoring

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Firecracker Host Pool musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Firecracker Host Pool musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Firecracker Host Pool, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Firecracker Host Pool oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Walidacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W18. Application Catalog

Globalny katalog autoryzowanych aplikacji i trybów: desktop, web, Android-native, limited/works/broken.

Zakres funkcjonalny

Cel modułu

Globalny katalog autoryzowanych aplikacji i trybów: desktop, web, Android-native, limited/works/broken.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Admin, Operator Panel, Workload Images

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Application Catalog musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Application Catalog musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Application Catalog, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Application Catalog oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W19. Application Environments

Instancje komunikatorów i narzędzi: Signal, Telegram, WhatsApp, Threema, Zangi, DuckDuckGo, LibreOffice, Exodus.

Zakres funkcjonalny

Cel modułu

Instancje komunikatorów i narzędzi: Signal, Telegram, WhatsApp, Threema, Zangi, DuckDuckGo, LibreOffice, Exodus.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Workload Orchestrator, Streaming, CDR, Monitoring

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Application Environments musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Application Environments musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Application Environments, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloads albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Application Environments oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Walidacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W20. CDR Pipeline

Granica transferu plików: allow/deny/quarantine, hash, transform, unsupported formats i evidence chain.

Zakres funkcjonalny

Cel modułu

Granica transferu plików: allow/deny/quarantine, hash, transform, unsupported formats i evidence chain.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Operator Panel, Workloads, Admin SOC

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

CDR Pipeline musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł CDR Pipeline musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla CDR Pipeline, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu CDR Pipeline oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W21. Matrix Server Addon

Opcjonalny własny Matrix, polityka federacji, CDR, monitoring metadanych i add-on billing.

Zakres funkcjonalny

Cel modułu

Opcjonalny własny Matrix, polityka federacji, CDR, monitoring metadanych i add-on billing.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Operator Panel, Workloads, Provider Registry

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Matrix Server Addon musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Matrix Server Addon musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Matrix Server Addon, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Matrix Server Addon oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W22. Backup/Panic Policy

Backup operatora, restore, inactivity wipe, panic levels i legal pre-approval dla działań destrukcyjnych.

Zakres funkcjonalny

Cel modułu

Backup operatora, restore, inactivity wipe, panic levels i legal pre-approval dla działań destrukcyjnych.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Operator Panel, Admin, Audit, Storage

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Backup/Panic Policy musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Backup/Panic Policy musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Backup/Panic Policy, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Backup/Panic Policy oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W23. Jurisdiction Rotation

Rotacja krajów/providerów według tieru, reuse sanitized pools i dedykacja wyższych tierów.

Zakres funkcjonalny Cel modułu Rotacja krajów/providerów według tieru, reuse sanitized pools i dedykacja wyższych tierów. Użytkownik lub system Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate. Główne zależności Subscription Policy, Provider Registry, G1/G2, Workloads Wyjście modułu Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.
Ekrany, API i dane Ekrany/UI Jurisdiction Rotation musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka. API Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id. Model danych Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów. Sekrety Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.
Kontrole bezpieczeństwa RBAC i step-up Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka. Granice danych Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora. Audit Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id. Fail closed Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.
Awaryjne i scenariusze naprawy Typowe awarie Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity. Reakcja systemu Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu. Rollback Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy. Obsługa support Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Jurisdiction Rotation musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Jurisdiction Rotation, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Jurisdiction Rotation oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W24. Monitoring/SIEM

Blue-team metadane bez treści: health, route, auth, CDR, provider, cost, workload, anomaly score.

Zakres funkcjonalny

Cel modułu

Blue-team metadane bez treści: health, route, auth, CDR, provider, cost, workload, anomaly score.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

All Components, Admin Dashboard, Incident Response

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Monitoring/SIEM musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Monitoring/SIEM musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Monitoring/SIEM, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Monitoring/SIEM oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Walidacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W25. Anomaly Engine

Ocena P0-P3 z sygnałów routingu, kluczy, CDR, workload, providerów i admin actions.

Zakres funkcjonalny

Cel modułu

Ocena P0-P3 z sygnałów routingu, kluczy, CDR, workload, providerów i admin actions.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Monitoring, Admin, Audit, Incident Response

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Anomaly Engine musi mieć widok listy/statusu, widok szczegółów, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Anomaly Engine musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Anomaly Engine, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloads albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Anomaly Engine oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W26. Incident Response

Containment, revoke, rebuild, rotate, quarantine, postmortem i ownery dla każdego alertu.

Zakres funkcjonalny

Cel modułu

Containment, revoke, rebuild, rotate, quarantine, postmortem i ownery dla każdego alertu.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Admin, Monitoring, G1/G2, Workloads, Audit

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Incident Response musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Incident Response musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Incident Response, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Incident Response oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W27. Audit/WORM Evidence

Niezmienny zapis tokenów, płatności, admin actions, provisioning, CDR, incidents i release gates.

Zakres funkcjonalny

Cel modułu

Niezmienny zapis tokenów, płatności, admin actions, provisioning, CDR, incidents i release gates.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Portal, Admin, Operator, SRE, SOC

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Audit/WORM Evidence musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Audit/WORM Evidence musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Audit/WORM Evidence, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Audit/WORM Evidence oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Walidacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W28. PKI/HSM/FIDO2

CA, certyfikaty, device certs, step-up, HSM/FIDO2 UI i późniejsze hardware acceptance tests.

Zakres funkcjonalny

Cel modułu

CA, certyfikaty, device certs, step-up, HSM/FIDO2 UI i późniejsze hardware acceptance tests.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Admin, Device Admission, G1/G2, Operator Security

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

PKI/HSM/FIDO2 musi mieć widok listy/statusu, widok szczegółów, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł PKI/HSM/FIDO2 musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla PKI/HSM/FIDO2, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu PKI/HSM/FIDO2 oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Validacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W29. Cost Engine

Koszt operatora: G1, G2, workload, bare metal share, transfer, storage, add-ons i provider capacity.

Zakres funkcjonalny

Cel modułu

Koszt operatora: G1, G2, workload, bare metal share, transfer, storage, add-ons i provider capacity.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Provider Registry, Subscriptions, Admin Dashboard

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Cost Engine musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Cost Engine musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Cost Engine, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Cost Engine oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Walidacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W30. Human Regression Lab

Testy jak człowiek przez Pixel/laptop: klik, wpisywanie, scroll, aplikacje, reset, streaming, przełączanie.

Zakres funkcjonalny

Cel modułu

Testy jak człowiek przez Pixel/laptop: klik, wpisywanie, scroll, aplikacje, reset, streaming, przełączanie.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

Pixel ADB, Playwright, Operator Panel, Workloads

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Human Regression Lab musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Human Regression Lab musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Human Regression Lab, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Human Regression Lab oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Walidacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.

W31. Release Gates

System decyzyjny works/partial/blocked oparty o E0-E8, testy negatywne, dowody i human gate.

Zakres funkcjonalny

Cel modułu

System decyzyjny works/partial/blocked oparty o E0-E8, testy negatywne, dowody i human gate.

Użytkownik lub system

Portal/Admin/Operator/SRE/SOC zależnie od modułu; odpowiedzialność musi być przypisana w backlogu i release gate.

Główne zależności

All Modules, Admin, Audit

Wyjście modułu

Stan systemowy możliwy do sprawdzenia przez API, UI, audit event i test automatyczny. Moduł nie może opierać się na ręcznej deklaracji bez dowodu.

Ekrany, API i dane

Ekrany/UI

Release Gates musi mieć widok listy/statusu, widok szczegółu, stany loading/error/empty oraz jasne akcje operatora/admina, jeżeli moduł ma interakcję człowieka.

API

Każda mutacja ma endpoint idempotentny albo jawnie transakcyjny, walidację wejścia, RBAC, audit actor, request_id i correlation_id.

Model danych

Encje muszą mieć ownera tenant/operator, status lifecycle, created/updated timestamps, policy_version i bezpieczne pola do audytu bez sekretów.

Sekrety

Sekrety nie są wyświetlane po zapisie. UI pokazuje configured/not configured, fingerprint, serial albo publiczny identyfikator.

Kontrole bezpieczeństwa

RBAC i step-up

Operacje krytyczne wymagają roli, step-up albo four-eyes. Działania PHANTOM wymagają human gate i oddzielnej akceptacji ryzyka.

Granice danych

Moduł nie może ujawniać treści wiadomości, seedów, haseł, kodów SMS, kluczy prywatnych ani zawartości prywatnych plików operatora.

Audit

Każda mutacja zapisuje WORM event: actor, action, target, safe diff, reason, result i correlation_id.

Fail closed

Przy braku policy, braku providera, braku certyfikatu, błędzie webhooka albo braku tunelu moduł ma blokować akcję zamiast tworzyć stan niejawny.

Awarie i scenariusze naprawy

Typowe awarie

Timeout, provider API failure, stale policy, quota exceeded, missing package, stream unreachable, race condition, failed audit write, out-of-capacity.

Reakcja systemu

Status przechodzi do failed/blocked/partial z czytelnym kodem błędu. Retry musi być idempotentny i widoczny w admin panelu.

Rollback

Rollback nie może usuwać evidence. Przy działaniach destrukcyjnych najpierw zamrożenie i zapis decyzji, potem dopiero wykonanie policy.

Obsługa support

Support widzi stan i metadane, ale nie widzi sekretów ani prywatnej treści operatora.

Obserwowalność w panelu administratora

Status główny

Moduł Release Gates musi raportować healthy/degraded/blocked, ostatnią zmianę stanu, ownera, wpływ na operatorów i link do ostatniego audytu.

Metryki

Minimalne metryki: success rate, latency p50/p95/p99, error rate, queue depth lub active sessions, koszt/capacity jeżeli dotyczy oraz liczba alertów P0-P3.

Alerty

Alert musi mieć severity, short reason, affected tenant/operator, affected component, first_seen, last_seen, runbook link, owner i możliwą akcję containment.

Zakaz

Panel nie może rozwiązywać problemu przez pokazanie sekretu, plaintext tokenu, seed, prywatnego pliku, treści wiadomości ani nagrania streamu.

Backlog implementacyjny

P0

Zbudować minimalny kontrakt API/event dla Release Gates, RBAC, audit event, status lifecycle i test negatywny dla braku uprawnień.

P1

Dodać UI z empty/loading/error/success states, filtry, sortowanie, szczegóły rekordu i bezpieczne komunikaty błędów.

P2

Dodać raport kosztów albo capacity, jeżeli moduł ma wpływ na billing, providerów, workloady albo czas sesji.

Dokumentacja

Każdy endpoint, status, event i gate ma mieć krótki opis w Księdze albo ADR oraz przykład oczekiwanego audit event.

Definition of done

Moduł ma status works dopiero po przejściu testów kontraktowych, integracyjnych, negatywnych i human regression, jeżeli dotyczy terminala/operatora.

Testy i dowody

Test podstawowy

Playwright/API test potwierdza happy path modułu Release Gates oraz zapis audytu.

Test negatywny

Nieprawidłowy scope, brak entitlement, błędny podpis, próba cross-tenant albo brak wymaganej roli muszą zostać odrzucone.

Test human

Jeżeli moduł wpływa na Pixel/laptop/operator panel, wymagany jest test człowieka: klik, wpisywanie, scroll, przełączenie i powrót.

Kryterium works

Status works jest dozwolony dopiero po E5/E6 tam, gdzie moduł dotyka usability albo granicy bezpieczeństwa.

Macierz testów modułu

E2 API contract

Walidacja schematów request/response/event, RBAC, status codes, idempotency i bezpiecznych błędów.

E3 Integration

Przepływ przez zależności modułu musi działać bez ręcznych zmian w bazie i bez mocków w ścieżce produkcyjnej.

E4 Live probe

Sonda metadanych ma potwierdzić reachability albo poprawny status blocked/degraded w realnym środowisku.

E5 Human regression

Jeżeli moduł wpływa na UI/terminal/aplikację, człowiek albo ADB/Playwright musi wykonać realny workflow.

E6 Security negative

Cross-tenant, forged event, replay, stale policy, direct bypass i brak entitlement muszą kończyć się deny.

E7 Regression

Test musi być powtarzalny w CI/staging/live-safe i zapisywać artefakt do katalogu evidence.